

AR300, AR700
V300R021

配置指南-安全（命令行）

文档版本	02
发布日期	2024-11-20



版权所有 © 华为技术有限公司 2024。保留一切权利。

非经本公司书面许可，任何单位和个人不得擅自摘抄、复制本文档内容的部分或全部，并不得以任何形式传播。

商标声明



HUAWEI和其他华为商标均为华为技术有限公司的商标。

本文档提及的其他所有商标或注册商标，由各自的所有人拥有。

注意

您购买的产品、服务或特性等应受华为公司商业合同和条款的约束，本文档中描述的全部或部分产品、服务或特性可能不在您的购买或使用范围之内。除非合同另有约定，华为公司对本文档内容不做任何明示或暗示的声明或保证。

由于产品版本升级或其他原因，本文档内容会不定期进行更新。除非另有约定，本文档仅作为使用指导，本文档中的所有陈述、信息和建议不构成任何明示或暗示的担保。

华为技术有限公司

地址：深圳市龙岗区坂田华为总部办公楼 邮编：518129

网址：<https://ekit.huawei.com>

前言

读者对象

本文档介绍了AR中安全特性的基本概念、在不同应用场景中的配置过程和配置举例。

本文档提供了安全特性的配置方法。

本文档主要适用于以下工程师：

- 数据配置工程师
- 调测工程师
- 网络监控工程师
- 系统维护工程师

符号约定

在本文中可能出现下列标志，它们所代表的含义如下。

符号	说明
	表示如不可避免则将会导致死亡或严重伤害的具有高等级风险的危害。
	表示如不可避免则可能导致死亡或严重伤害的具有中等级风险的危害。
	表示如不可避免则可能导致轻微或中度伤害的具有低等级风险的危害。
	用于传递设备或环境安全警示信息。如不可避免则可能会导致设备损坏、数据丢失、设备性能降低或其它不可预知的结果。 “须知”不涉及人身伤害。

符号	说明
 说明	对正文中重点信息的补充说明。 “说明”不是安全警示信息，不涉及人身、设备及环境伤害信息。

命令行格式约定

在本文中可能出现下列命令行格式，它们所代表的含义如下。

格式	意义
粗体	命令行关键字（命令中保持不变、必须照输的部分）采用 加粗 字体表示。
<i>斜体</i>	命令行参数（命令中必须由实际值进行替代的部分）采用 <i>斜体</i> 表示。
[]	表示用“[]”括起来的部分在命令配置时是可选的。
{ x y ... }	表示从两个或多个选项中选取一个。
[x y ...]	表示从两个或多个选项中选取一个或者不选。
{ x y ... } *	表示从两个或多个选项中选取多个，最少选取一个，最多选取所有选项。
[x y ...] *	表示从两个或多个选项中选取多个或者不选。
&<1-n>	表示符号&的参数可以重复1～n次。
#	由“#”开始的行表示为注释行。

接口编号约定

本手册中出现的接口编号仅作示例，并不代表设备上实际具有此编号的接口，实际使用中请以设备上存在的接口编号为准。

安全约定

- 密码配置约定
 - 配置密码时请尽量选择密文模式(cipher)。为充分保证设备安全，请用户不要关闭密码复杂度检查功能，并定期修改密码。
 - 配置明文模式的密码时，请不要以“%@@@.....%@@@”或“@%@@.....@%@@%”或“%#%#.....%#%#”或“%^%#.....%^%#”作为起始和结束符。因为用这些字符为起始和结束符的是合法密文（本设备可以解密的密文），配置文件会显示与用户配置相同的明文。

- 配置密文密码时，不同特性的密文密码不能互相使用。例如AAA特性生成的密文密码不能用于配置其他特性的密文密码。
- 加密算法约定
目前设备采用的加密算法包括3DES、AES、RSA、SHA1、SHA2和MD5。3DES、RSA和AES加密算法是可逆的，SHA1、SHA2和MD5加密算法是不可逆的。DES/3DES/RSA(1024位以下)/MD5(数字签名场景和口令加密)/SHA1(数字签名场景)加密算法安全性低，存在安全风险。在协议支持的加密算法选择范围内，建议使用更安全的加密算法，比如AES/RSA(2048位以上)/SHA2/HMAC-SHA2。具体采用哪种加密算法请根据场景而定：对于管理员类型的密码，必须采用不可逆加密算法，推荐使用安全性更高的SHA2。
- 个人数据约定
您购买的产品、服务或特性在业务运营或故障定位的过程中将可能获取或使用用户的某些个人数据（如终端用户的MAC地址或IP地址），因此您有义务根据所适用国家的法律制定必要的用户隐私政策并采取足够的措施以确保用户的个人数据受到充分的保护。
- 本文档中出现的“镜像端口、端口镜像、流镜像、镜像”等相关词汇仅限于为了描述该产品进行检测通信传输中的故障和错误的目的而使用，不涉及采集、处理任何个人数据或任何用户通信内容。

参考标准和协议

请登录[华为网站](#)，搜索“标准协议遵从表”，获取《华为AR路由器标准协议遵从表》。

特别声明

- 本手册仅作为使用指导，其内容（如Web界面、CLI命令格式、命令输出）依据实验室设备信息编写。手册提供的内容具有一般性的指导意义，并不确保涵盖所有型号产品的所有使用场景。因版本升级、设备型号不同、配置文件不同等原因，可能造成手册中提供的内容与用户使用的设备界面不一致。请以用户设备界面的信息为准，本手册不再针对前述情况造成的差异一一说明。
- 本手册中提供的最大值是设备在实验室特定场景（例如，被测试设备上只有某种类型的单板，或者只配置了某一种协议）达到的最大值。在现实网络中，由于设备硬件配置不同、承载的业务不同等原因会使设备测试出的最大值与手册中提供的数据不一致。
- 出于特性介绍及配置示例的需要，本文档可能会使用公网IP地址，如无特殊说明出现的公网IP地址均为示意，不指代任何实际意义。
- 出于配置示例的需要，文档中出现VLANIF接口的案例仅作为示例，并不代表设备上实际支持的接口，实际配置中请以设备支持的接口为准。

产品软件和网管软件版本配套关系

产品软件和网管软件版本配套关系如下所示。

AR产品软件版本	eSight网管软件版本	iMaster NCE-CampusInsight
V300R021C00	V300R010C00SPC639	V100R021C00SPC100
V300R021C10	eSight 21.2.0	V100R021C10SPC100

目 录

前言..... ii

1 AAA 配置..... 1

1.1 AAA 简介..... 1

1.2 AAA 原理描述..... 2

1.2.1 基于域的用户管理..... 2

1.2.2 AAA 方案..... 6

1.2.2.1 认证方案..... 6

1.2.2.2 授权方案..... 7

1.2.2.3 计费方案..... 9

1.2.3 本地认证和授权..... 10

1.2.4 RADIUS 认证、授权和计费..... 11

1.2.4.1 RADIUS 概述..... 11

1.2.4.2 RADIUS 报文介绍..... 12

1.2.4.3 RADIUS 认证、授权、计费流程..... 15

1.2.4.4 RADIUS 报文重传机制..... 16

1.2.4.5 RADIUS 服务器选择机制..... 18

1.2.4.6 RADIUS 服务器状态探测..... 19

1.2.4.7 RADIUS CoA/DM..... 26

1.2.4.8 RADIUS 属性..... 30

1.2.4.9 RADIUS 属性禁用和转换功能..... 54

1.2.5 HWTACACS 认证、授权、计费..... 56

1.2.5.1 HWTACACS 概述..... 56

1.2.5.2 HWTACACS 报文介绍..... 57

1.2.5.3 HWTACACS 认证、授权、计费流程..... 66

1.2.5.4 HWTACACS 属性..... 67

1.2.6 HACA 认证、授权、计费..... 72

1.2.6.1 HACA 概述..... 72

1.2.6.2 HACA 业务报文类型介绍..... 73

1.2.6.3 HACA 认证、授权、计费流程..... 74

1.3 AAA 应用场景..... 76

1.4 AAA 配置注意事项..... 78

1.5 AAA 缺省配置..... 79

1.6 AAA 配置任务概览..... 79

1.7 配置采用本地方式进行认证和授权.....	80
1.7.1 配置本地服务器.....	81
1.7.1.1 配置本地用户.....	81
1.7.1.2 配置授权规则.....	87
1.7.2 配置 AAA 方案.....	88
1.7.3 配置业务方案.....	89
1.7.4 在域下应用 AAA 方案.....	91
1.7.5 检查 AAA 的配置结果.....	93
1.8 配置采用 RADIUS 方式进行认证、授权和计费.....	93
1.8.1 配置 AAA 方案.....	94
1.8.2 配置 RADIUS 服务器模板.....	96
1.8.3 （可选）配置 RADIUS 服务器状态探测功能.....	99
1.8.4 （可选）配置 RADIUS 属性.....	101
1.8.4.1 配置 RADIUS 属性禁用和转换功能.....	101
1.8.4.2 配置 RADIUS 属性检查功能.....	102
1.8.4.3 更改 RADIUS 属性值.....	102
1.8.4.4 配置 RADIUS 标准属性.....	103
1.8.4.5 配置华为 RADIUS 扩展属性.....	104
1.8.5 （可选）配置授权信息.....	105
1.8.5.1 配置业务方案.....	105
1.8.5.2 配置用户组.....	107
1.8.6 创建域和配置域.....	107
1.8.7 配置全局默认域.....	109
1.8.8 在域下应用 AAA 方案、RADIUS 服务器模板和授权信息.....	110
1.8.9 配置 RADIUS CoA/DM 功能.....	111
1.8.10 检查 AAA 的配置结果.....	113
1.9 配置采用 HWTACACS 方式进行认证、授权和计费.....	113
1.9.1 配置 HWTACACS 服务器.....	114
1.9.2 配置 AAA 方案.....	114
1.9.3 配置 HWTACACS 服务器模板.....	117
1.9.4 （可选）配置记录方案.....	120
1.9.5 配置业务方案.....	121
1.9.6 在域下应用 AAA 方案.....	123
1.9.7 检查 AAA 的配置结果.....	125
1.10 配置采用 HACA 方式进行认证.....	126
1.10.1 配置 HACA 服务器.....	126
1.10.2 配置 AAA 方案.....	126
1.10.3 配置 HACA 服务器模板.....	128
1.10.4 配置业务方案.....	129
1.10.5 在域下应用 AAA 方案.....	131
1.10.6 检查配置结果.....	132
1.11 维护 AAA.....	133

1.11.1 强制在线用户下线.....	133
1.11.2 测试单个用户能否通过 RADIUS 认证或计费.....	133
1.11.3 配置 AAA 告警上报功能.....	135
1.11.4 记录用户上、下线信息.....	136
1.11.5 清除 AAA 统计信息.....	136
1.11.6 清除 HACA 统计信息.....	137
1.12 AAA 配置举例.....	137
1.12.1 配置主备 RADIUS 服务器示例.....	138
1.12.2 配置主备 HWTACACS 服务器示例.....	141
1.12.3 配置基于默认域的用户管理示例.....	145
1.12.4 配置采用 HACA 协议进行认证和计费示例.....	150
1.13 AAA FAQ.....	152
1.13.1 为什么在使用 AAA 认证方式时，管理员用户不能使用不认证.....	152
1.13.2 RADIUS 模板下的配置正确且 AAA 的认证方式为 RADIUS，RADIUS 服务器用户配置正确，为什么认证总是失败.....	152
1.13.3 为什么 RADIUS 动态授权总是出现服务器检查失败.....	152
1.13.4 TACACS 模板下的配置正确且 AAA 的认证方式为 HWTACACS，TACACS 服务器用户配置正确，为什么认证总是失败.....	152
1.13.5 在设备上执行命令时，为什么总会在 TACACS 服务器收到计费报文.....	153
1.13.6 display access-user 时，为何有时不能显示 802.1x 用户的 IP 地址.....	153
1.13.7 RADIUS 动态下发 ACL 需要哪几个属性.....	153
1.13.8 RADIUS 动态下发 VLAN 需要哪几个属性.....	153
1.13.9 配置 HWTACACS 有哪些限制.....	153
1.13.10 设备支持 RADIUS 配置用户的级别吗，如何实现.....	153
1.13.11 为什么在 Radius 服务器上配置用户级别是 1 级，但是用户登录后能使用超过级别超过 1 级的命令.....	154
1.13.12 AR 替换 ME60 设备后，如何转换 RADIUS 属性实现对接？.....	154
2 DAA 配置.....	155
2.1 DAA 简介.....	155
2.2 DAA 原理描述.....	155
2.3 DAA 应用场景.....	157
2.4 DAA 配置任务概览.....	157
2.5 DAA 配置注意事项.....	158
2.6 DAA 缺省配置.....	159
2.7 配置 DAA.....	159
2.7.1 配置流量识别规则.....	160
2.7.2 配置流量的费率级别.....	160
2.7.3 配置流量计费.....	161
2.7.4 检查配置结果.....	162
2.8 DAA 配置举例.....	162
2.8.1 配置对指定网络进行计费示例.....	162
3 NAC 配置.....	167
3.1 NAC 原理描述.....	167

3.1.1 NAC 概述.....	167
3.1.2 802.1X 认证原理描述.....	168
3.1.2.1 802.1X 认证简介.....	168
3.1.2.2 802.1X 认证协议.....	169
3.1.2.3 802.1X 认证流程.....	174
3.1.2.4 802.1X 授权.....	177
3.1.2.5 802.1X 重认证.....	178
3.1.2.6 802.1X 认证用户下线.....	179
3.1.2.7 802.1X 定时器.....	182
3.1.3 MAC 认证原理描述.....	185
3.1.3.1 MAC 认证简介.....	185
3.1.3.2 MAC 认证流程.....	186
3.1.3.3 MAC 认证授权.....	187
3.1.3.4 MAC 认证重认证.....	188
3.1.3.5 MAC 认证用户下线.....	189
3.1.3.6 MAC 认证静默定时器.....	191
3.1.4 Portal 认证原理描述.....	192
3.1.4.1 Portal 认证简介.....	192
3.1.4.2 Portal 认证协议.....	193
3.1.4.2.1 Portal 协议.....	193
3.1.4.3 Portal 认证方式.....	198
3.1.4.4 Portal 认证流程.....	199
3.1.4.4.1 基于 Portal 协议的 Portal 认证流程.....	199
3.1.4.4.2 基于 HTTP/HTTPS 协议的 Portal 重定向流程.....	201
3.1.4.5 Portal 认证授权.....	204
3.1.4.6 Portal 认证用户下线.....	205
3.1.4.7 Portal 定时器.....	209
3.1.5 混合认证.....	216
3.1.5.1 MAC 旁路认证.....	216
3.1.5.2 MAC 优先的 Portal 认证.....	217
3.1.6 NAC 逃生机制.....	219
3.1.7 NAC 认证逻辑流程.....	220
3.1.7.1 802.1X 认证逻辑流程.....	220
3.1.7.2 MAC 认证逻辑流程.....	222
3.1.7.3 Portal 认证逻辑流程.....	222
3.2 NAC 应用场景.....	225
3.3 NAC 配置注意事项.....	226
3.4 NAC 缺省配置.....	227
3.5 配置 NAC.....	228
3.5.1 NAC 配置流程.....	228
3.5.2 配置接入模板.....	230
3.5.2.1 配置 802.1X 接入模板.....	230

3.5.2.1.1 创建 802.1X 接入模板.....	230
3.5.2.1.2 配置 802.1X 接入模板.....	230
3.5.2.1.3 （可选）配置 802.1X 客户端无响应时的网络访问权限.....	232
3.5.2.1.4 （可选）配置对在线 802.1X 用户进行重认证.....	233
3.5.2.1.5 （可选）配置 802.1X 定时器.....	234
3.5.2.1.6 （可选）配置动态 VLAN 功能.....	235
3.5.2.1.7 检查 802.1X 接入模板配置结果.....	235
3.5.2.2 配置 MAC 接入模板.....	235
3.5.2.2.1 创建 MAC 接入模板.....	236
3.5.2.2.2 配置 MAC 接入模板.....	236
3.5.2.2.3 （可选）配置对在线 MAC 用户进行重认证.....	237
3.5.2.2.4 （可选）配置动态 VLAN 功能.....	238
3.5.2.2.5 检查 MAC 接入模板配置结果.....	239
3.5.3 配置认证模板.....	239
3.5.3.1 创建认证模板.....	239
3.5.3.2 配置认证模板.....	239
3.5.3.3 （可选）配置认证事件授权信息.....	242
3.5.3.4 （可选）配置用户的免认证授权信息.....	244
3.5.3.5 （可选）配置对用户进行重认证.....	245
3.5.3.6 检查认证模板配置结果.....	246
3.5.4 应用 NAC.....	246
3.5.5 （可选）配置 NAC 扩展功能.....	247
3.5.5.1 配置 802.1X 认证相关的扩展功能.....	247
3.5.5.1.1 配置发送 802.1X 认证请求报文的时间间隔.....	247
3.5.5.1.2 配置 802.1X 快速部署功能.....	248
3.5.5.1.3 配置设备允许记录的异常 802.1X 认证的 EAP 报文数.....	249
3.5.5.1.4 配置 HTTPS 重定向功能.....	249
3.5.5.2 配置 Portal 认证相关的扩展功能.....	249
3.5.5.2.1 配置 iOS 系统的 CNA 旁路功能.....	249
3.5.5.2.2 配置 iOS 系统的 CNA 自适应功能.....	250
3.5.5.2.3 配置允许接入的 Portal 认证用户数.....	251
3.5.5.2.4 （可选）配置 3G/LTE 链路断开连接后，强制 Portal 认证用户下线.....	251
3.5.5.3 配置用户静默功能.....	252
3.5.5.4 配置 WEB 页面推送功能.....	253
3.5.5.5 （可选）配置 HTTP 协议认证计费功能.....	254
3.5.5.6 配置允许用户连续认证失败的最大次数.....	255
3.5.5.7 调整 ACL 规则的匹配顺序.....	256
3.5.5.8 配置用户隔离功能.....	256
3.5.5.9 配置用户下线探测报文源地址.....	256
3.5.5.10 使能动态调整 NAC 用户报文处理速率功能.....	258
3.5.5.11 配置 URL 编解码功能.....	258
3.5.5.12 配置 NAC 认证用户数的告警阈值.....	258

3.5.5.13 配置 AP 为免认证用户.....	259
3.5.5.14 检查 NAC 扩展功能配置结果.....	259
3.6 维护 NAC.....	260
3.6.1 配置 NAC 告警上报功能.....	260
3.6.2 清除 NAC 认证统计信息.....	261
3.6.3 监控 NAC 认证运行状况.....	261
3.7 NAC 配置举例.....	261
3.7.1 配置 802.1X 认证示例.....	262
3.7.2 配置 MAC 认证示例.....	265
3.7.3 配置外置二层 Portal 认证示例.....	268
3.7.4 配置外置二层 Portal 认证示例（使用重定向参数）.....	272
3.7.5 配置外置三层 Portal 认证示例.....	276
3.7.6 配置 802.1X 认证示例（AAA 采用 RADIUS 方式）.....	281
3.8 NAC FAQ.....	287
3.8.1 802.1x 用户动态 VLAN 什么情况下才能生效.....	287
3.8.2 display access-user 时，为何有时不能显示 802.1x 用户的 IP 地址.....	287
3.8.3 802.1x 用户采用域配置的优先级顺序.....	287
3.8.4 MAC 旁路认证功能能否在主控板的固定接口上进行配置.....	288
4 终端接入配置.....	289
4.1 终端接入简介.....	289
4.2 终端接入配置注意事项.....	290
4.3 配置终端接入.....	291
4.4 终端接入配置举例.....	294
4.4.1 配置 Portal 认证的终端接入示例.....	294
4.4.2 配置 PPPoE 认证的终端接入示例.....	299
5 ACL 配置.....	304
5.1 ACL 简介.....	304
5.2 ACL 原理描述.....	306
5.2.1 ACL 的基本原理.....	306
5.2.2 ACL 的分类.....	309
5.2.3 ACL 的步长设定.....	310
5.2.4 ACL 的匹配顺序.....	312
5.2.5 ACL 的常用匹配项.....	314
5.2.6 ACL 的生效时间段.....	322
5.2.7 ACL 应用模块的 ACL 默认动作和处理机制.....	323
5.2.8 ACL 的常用配置原则.....	330
5.3 ACL 应用场景.....	333
5.3.1 使用 ACL 限制 Telnet 登录权限.....	333
5.3.2 使用 ACL 限制不同网段用户的互访.....	333
5.3.3 使用 ACL 禁止特定用户主机在特定时间内上网.....	335
5.3.4 在 QoS 中使用 ACL 实施流量监管.....	335
5.3.5 在 OSPF 中使用 ACL 过滤路由信息.....	337

5.3.6 在 SNMP 中使用 ACL 过滤非法网管.....	337
5.3.7 在 NAT 中使用 ACL 过滤流量.....	338
5.3.8 在防火墙中使用 ACL 防止外网入侵内网.....	339
5.4 ACL 配置任务概览.....	340
5.5 ACL 配置注意事项.....	341
5.6 ACL 缺省配置.....	342
5.7 配置 ACL.....	342
5.7.1 配置并应用基本 ACL.....	342
5.7.1.1 （可选）配置 ACL 的生效时间段.....	342
5.7.1.2 （可选）配置端口集.....	344
5.7.1.3 配置基本 ACL.....	344
5.7.1.4 应用基本 ACL.....	346
5.7.1.5 检查基本 ACL 配置结果.....	349
5.7.2 配置并应用高级 ACL.....	350
5.7.2.1 （可选）配置 ACL 的生效时间段.....	350
5.7.2.2 配置高级 ACL.....	350
5.7.2.3 应用高级 ACL.....	353
5.7.2.4 检查高级 ACL 配置结果.....	355
5.7.3 配置并应用二层 ACL.....	355
5.7.3.1 （可选）配置 ACL 的生效时间段.....	355
5.7.3.2 配置二层 ACL.....	355
5.7.3.3 应用二层 ACL.....	357
5.7.3.4 检查二层 ACL 配置结果.....	358
5.7.4 配置并应用用户 ACL.....	358
5.7.4.1 （可选）配置 ACL 的生效时间段.....	358
5.7.4.2 配置用户 ACL.....	359
5.7.4.3 应用用户 ACL.....	360
5.7.4.4 检查用户 ACL 配置结果.....	361
5.7.5 配置并应用基本 ACL6.....	361
5.7.5.1 （可选）配置 ACL6 的生效时间段.....	361
5.7.5.2 配置基本 ACL6.....	361
5.7.5.3 应用基本 ACL6.....	363
5.7.5.4 检查基本 ACL6 配置结果.....	365
5.7.6 配置并应用高级 ACL6.....	365
5.7.6.1 （可选）配置 ACL6 的生效时间段.....	365
5.7.6.2 配置高级 ACL6.....	366
5.7.6.3 应用高级 ACL6.....	368
5.7.6.4 检查高级 ACL6 配置结果.....	370
5.8 维护 ACL.....	370
5.8.1 调整 ACL 规则的步长.....	370
5.8.2 查看 ACL 的资源信息.....	371
5.8.3 优化 ACL 资源.....	371

5.8.4 清除 ACL 的统计信息.....	372
5.9 ACL 配置举例.....	372
5.9.1 使用基本 ACL 限制 FTP 访问权限示例.....	372
5.9.2 使用基本 ACL 限制 Telnet 登录权限示例.....	374
5.9.3 SNMP 中应用基本 ACL 过滤非法网管示例（SNMPv1）.....	376
5.9.4 SNMP 中应用基本 ACL 过滤非法网管示例（SNMPv3）.....	380
5.9.5 在 OSPF 中使用基本 ACL 过滤路由信息示例.....	383
5.9.6 使用基本 ACL 实现配置 URPF 来防止基于源地址欺骗示例.....	388
5.9.7 使用高级 ACL 限制不同网段的用户互访示例.....	389
5.9.8 使用高级 ACL 限制用户在特定时间访问特定服务器的权限示例.....	393
5.9.9 应用高级 ACL 配置防火墙示例.....	398
5.9.10 使用二层 ACL 禁止特定用户上网示例.....	401
5.9.11 在 QoS 中使用二层 ACL 实施流量监管示例.....	404
5.9.12 使用高级 ACL6 过滤特定 IPv6 报文示例.....	409
5.10 ACL 常见配置错误.....	411
5.10.1 IP 地址通配符掩码配置错误导致业务中断.....	411
5.10.2 误屏蔽 DNS 服务器地址导致用户无法上网.....	412
5.10.3 系统时间不正确导致基于时间的 ACL 不生效.....	412
5.11 ACL FAQ.....	413
5.11.1 ACL 下发主要有哪几种方式？.....	413
5.11.2 ACL 中的 permit/deny 与 traffic policy 中 behavior 的 permit/deny 之间是什么关系？.....	415
5.11.3 如何查看 ACL 的生效顺序？.....	416
5.11.4 如何实现单向访问控制？.....	416
5.11.5 应用在流策略中的 ACL 不支持对哪些报文进行过滤？.....	418
5.11.6 ACL 的 rule 中的 deny/permit 在各个业务模块里的场景是怎样的.....	418
6 防火墙配置.....	421
6.1 防火墙简介.....	422
6.2 防火墙原理描述.....	422
6.2.1 安全域.....	422
6.2.2 防火墙工作模式.....	423
6.2.3 包过滤防火墙.....	423
6.2.4 状态检测防火墙.....	424
6.2.5 黑名单.....	426
6.2.6 白名单.....	427
6.2.7 端口映射.....	428
6.2.8 攻击防范.....	428
6.2.9 流量统计及监控.....	435
6.2.10 防火墙日志.....	436
6.2.11 虚拟防火墙.....	437
6.2.12 防火墙主备.....	437
6.3 防火墙应用场景.....	440
6.3.1 防火墙应用在内外网之间.....	440

6.3.2 防火墙在内部网络中的应用.....	440
6.4 防火墙配置注意事项.....	441
6.5 防火墙缺省配置.....	441
6.6 配置防火墙基本功能.....	443
6.6.1 创建安全域并将接口加入安全区域.....	443
6.6.2 创建安全域间.....	444
6.6.3 在安全域间使能防火墙功能.....	444
6.6.4 （可选）配置防火墙会话表老化时间.....	445
6.6.5 检查防火墙基本功能的配置结果.....	445
6.7 配置包过滤防火墙.....	445
6.7.1 （可选）配置缺省过滤方式.....	445
6.7.2 配置 ACL 包过滤防火墙.....	446
6.7.3 检查包过滤防火墙的配置结果.....	447
6.8 配置状态检测防火墙（ASPF）.....	447
6.9 配置黑名单.....	448
6.9.1 使能黑名单.....	448
6.9.2 单条配置黑名单表项.....	449
6.9.3 批量配置黑/白名单表项.....	449
6.9.4 检查黑名单的配置结果.....	450
6.10 配置白名单.....	450
6.10.1 单条配置白名单表项.....	451
6.10.2 批量配置黑/白名单表项.....	451
6.10.3 检查白名单的配置结果.....	452
6.11 配置端口映射.....	452
6.12 配置攻击防范.....	453
6.12.1 使能攻击防范.....	453
6.12.2 配置 flood 类攻击防范参数.....	454
6.12.3 配置对超大 ICMP 报文的攻击防范.....	454
6.12.4 配置扫描类攻击防范参数.....	455
6.12.5 检查攻击防范的配置结果.....	455
6.13 配置流量统计和监控.....	455
6.13.1 配置系统级流量统计和监控功能.....	456
6.13.2 配置基于安全区域的流量统计和监控功能.....	456
6.13.3 配置基于 IP 的流量统计和监控.....	457
6.13.4 检查流量统计和监控的配置结果.....	457
6.14 配置防火墙日志.....	458
6.15 配置虚拟防火墙.....	459
6.15.1 配置 VPN 实例划分虚拟防火墙.....	459
6.15.2 配置虚拟防火墙的安全特性.....	459
6.15.3 检查虚拟防火墙的配置结果.....	461
6.16 配置防火墙主备.....	461
6.16.1 配置 HSB 主备服务.....	461

6.16.2 配置 HSB 备份组.....	462
6.16.3 使能 HSB 备份组.....	463
6.16.4 检查 VRRP 热备份配置结果.....	463
6.17 维护防火墙.....	463
6.17.1 查看防火墙配置.....	463
6.17.2 清除防火墙统计信息.....	465
6.17.3 清除防火墙应用层表项的统计信息.....	465
6.17.4 清除防火墙攻击防范的统计信息.....	465
6.18 防火墙配置举例.....	466
6.18.1 配置 ACL 包过滤防火墙典型示例.....	466
6.18.2 配置 ASPF 和端口映射示例.....	468
6.18.3 配置黑名单示例.....	471
6.18.4 配置虚拟防火墙黑名单示例.....	473
6.18.5 配置防火墙主备示例.....	477
6.18.6 配置通过端口过滤防火墙典型示例.....	482
6.19 防火墙 FAQ.....	484
6.19.1 如何清除、查看防火墙和 NAT 流表.....	484
6.19.2 如何查看包过滤防火墙配置的 ACL 命中计数.....	484
6.19.3 AR 防火墙 ASPF 支持哪些协议	484
6.19.4 黑名单（防火墙）产生方式.....	484
7 深度安全防御配置.....	485
7.1 安全策略.....	485
7.1.1 安全策略简介.....	485
7.1.2 安全策略原理描述.....	486
7.1.3 安全策略应用场景.....	491
7.2 IPS 配置.....	493
7.2.1 IPS 简介.....	493
7.2.2 IPS 原理描述.....	494
7.2.3 IPS 应用场景.....	497
7.2.3.1 使用 IPS 阻断入侵行为.....	497
7.2.4 IPS 配置注意事项.....	499
7.2.5 IPS 缺省配置.....	499
7.2.6 开启深度安全防御功能.....	502
7.2.7 升级 IPS 特征库.....	502
7.2.8 配置 IPS.....	505
7.2.8.1 （可选）配置 IPS 自定义签名.....	505
7.2.8.2 配置 IPS 模板.....	507
7.2.8.3 在安全策略下绑定 IPS 模板.....	511
7.2.8.4 在安全域间应用安全策略.....	511
7.2.8.5 （可选）控制 IPS 的日志发送功能.....	512
7.2.8.6 检查 IPS 功能配置结果.....	513
7.2.9 维护 IPS.....	514

7.2.9.1 查看 IPS 的统计信息.....	514
7.2.9.2 清除 IPS 的统计信息.....	514
7.2.10 IPS 配置举例.....	515
7.2.10.1 配置 IPS 阻断入侵行为示例.....	515
7.3 URL 过滤配置.....	518
7.3.1 URL 过滤简介.....	519
7.3.2 URL 过滤原理描述.....	519
7.3.2.1 URL 匹配方式.....	519
7.3.2.2 URL 过滤实现原理.....	522
7.3.2.3 URL 远程查询过程.....	525
7.3.3 URL 过滤应用场景.....	526
7.3.3.1 使用 URL 过滤规范上网行为.....	526
7.3.4 URL 过滤配置注意事项.....	527
7.3.5 开启深度安全防护功能.....	529
7.3.6 配置 URL 过滤.....	529
7.3.6.1 配置 URL 过滤模板.....	529
7.3.6.2 在安全策略下绑定 URL 过滤模板.....	533
7.3.6.3 在安全域间应用安全策略.....	534
7.3.6.4 （可选）控制 URL 过滤的生成日志功能.....	535
7.3.6.5 （可选）基于用户组配置 URL 过滤.....	536
7.3.6.6 （可选）配置远程查询服务.....	536
7.3.6.7 检查 URL 过滤配置结果.....	537
7.3.7 维护 URL 过滤.....	538
7.3.7.1 查看 URL 过滤的统计信息.....	538
7.3.7.2 清除 URL 过滤的统计信息.....	538
7.3.8 URL 过滤配置举例.....	539
7.3.8.1 配置 URL 过滤规范员工上网行为示例.....	539
7.4 反病毒配置（AV）.....	543
7.4.1 反病毒简介.....	543
7.4.2 反病毒应用场景.....	544
7.4.3 反病毒原理描述.....	544
7.4.4 反病毒配置注意事项.....	547
7.4.5 开启深度安全防护功能.....	548
7.4.6 升级反病毒特征库.....	548
7.4.7 配置反病毒.....	551
7.4.7.1 创建反病毒配置文件模板.....	551
7.4.7.2 在安全策略下绑定反病毒配置文件模板.....	553
7.4.7.3 在安全域间应用安全策略.....	554
7.4.7.4 （可选）控制反病毒的日志发送功能.....	555
7.4.7.5 检查反病毒功能配置结果.....	555
7.4.8 维护反病毒.....	556
7.4.8.1 查看反病毒统计信息.....	556

7.4.8.2 清除反病毒统计信息.....	556
7.4.9 反病毒配置举例.....	556
7.4.9.1 配置反病毒阻断入侵行为示例.....	556
8 本机防攻击配置.....	561
8.1 本机防攻击简介.....	561
8.2 本机防攻击配置注意事项.....	563
8.3 本机防攻击缺省配置.....	563
8.4 配置 CPU 防攻击.....	565
8.4.1 创建防攻击策略.....	565
8.4.2 配置黑名单.....	565
8.4.3 配置动态调节 CPCAR 速率.....	566
8.4.4 配置速率限制.....	567
8.4.5 配置协议优先级.....	567
8.4.6 配置动态链路保护功能.....	568
8.4.7 配置统一限速.....	569
8.4.8 应用防攻击策略.....	569
8.4.9 检查 CPU 防攻击配置结果.....	569
8.5 配置攻击溯源.....	570
8.5.1 创建防攻击策略.....	570
8.5.2 配置攻击溯源检查阈值.....	570
8.5.3 配置攻击溯源的溯源模式.....	571
8.5.4 配置攻击溯源防范的报文类型.....	571
8.5.5 配置攻击溯源事件上报功能.....	572
8.5.6 配置攻击溯源惩罚功能.....	572
8.5.7 应用防攻击策略.....	573
8.5.8 检查攻击溯源配置结果.....	573
8.6 配置用户级限速.....	573
8.6.1 使能用户级限速功能.....	573
8.6.2 配置用户级限速的限速值.....	574
8.6.3 查看用户级限速丢弃的报文数.....	574
8.7 维护本机防攻击.....	574
8.7.1 清除攻击溯源信息.....	575
8.7.2 清除上送 CPU 报文统计信息.....	575
8.8 本机防攻击配置举例.....	575
8.8.1 配置本机防攻击示例.....	575
8.9 本机防攻击常见配置错误.....	579
8.9.1 攻击溯源功能不生效.....	579
8.9.2 黑名单功能不生效.....	580
8.10 本机防攻击 FAQ.....	580
8.10.1 本机防攻击中，如果黑名单应用的 ACL 组中的规则超过规格，超过部分如何处理.....	580
8.10.2 如何配置 CPCAR.....	580
8.10.3 为什么配置了 CPCAR 限速值没有生效.....	581

9 攻击防范配置	582
9.1 攻击防范简介	582
9.2 攻击防范原理描述	583
9.2.1 畸形报文攻击防范	583
9.2.2 分片报文攻击防范	584
9.2.3 泛洪攻击防范	589
9.3 攻击防范应用场景	590
9.4 攻击防范配置注意事项	591
9.5 攻击防范缺省配置	591
9.6 配置畸形报文攻击防范	592
9.7 配置分片报文攻击防范	592
9.8 配置泛洪攻击防范	593
9.8.1 配置 TCP SYN 泛洪攻击防范	593
9.8.2 配置 UDP 泛洪攻击防范	594
9.8.3 配置 ICMP 泛洪攻击防范	594
9.8.4 检查泛洪攻击防范配置结果	595
9.9 清除攻击防范统计信息	595
9.10 攻击防范配置举例	595
9.10.1 配置攻击防范示例	595
10 流量抑制配置	598
10.1 流量抑制简介	598
10.2 流量抑制原理描述	599
10.2.1 流量抑制的基本原理	599
10.3 流量抑制应用场景	599
10.3.1 流量抑制的典型应用	599
10.4 流量抑制配置注意事项	600
10.5 流量抑制缺省配置	600
10.6 配置流量抑制	600
10.6.1 配置接口的流量抑制	600
10.6.2 配置 ICMP 报文流量抑制	601
10.6.3 检查流量抑制配置结果	602
10.7 流量抑制配置举例	602
10.7.1 配置流量抑制示例	602
10.8 流量抑制常见配置错误	604
10.8.1 广播流量抑制无效	604
10.9 流量抑制 FAQ	605
10.9.1 为什么配置的流量抑制与实际抑制效果不一致	605
11 ARP 安全配置	606
11.1 ARP 安全简介	606
11.2 ARP 安全原理描述	609
11.2.1 ARP 报文限速	609
11.2.2 ARP Miss 消息限速	610

11.2.3 ARP 表项严格学习.....	612
11.2.4 ARP 表项限制.....	614
11.2.5 ARP 表项固化.....	614
11.2.6 动态 ARP 检测.....	616
11.2.7 ARP 防网关冲突.....	619
11.2.8 发送免费 ARP 报文.....	620
11.2.9 ARP 报文内 MAC 地址一致性检查.....	622
11.2.10 ARP 报文合法性检查.....	622
11.2.11 DHCP 触发 ARP 学习.....	622
11.3 ARP 安全应用场景.....	622
11.3.1 防 ARP 泛洪攻击.....	622
11.3.2 防 ARP 欺骗攻击.....	623
11.4 ARP 安全配置注意事项.....	624
11.5 ARP 安全缺省配置.....	625
11.6 配置 ARP 安全.....	626
11.6.1 配置防 ARP 泛洪攻击.....	626
11.6.1.1 配置 ARP 报文限速（根据源 MAC 地址）.....	627
11.6.1.2 配置 ARP 报文限速（根据源 IP 地址）.....	627
11.6.1.3 配置 ARP 报文限速（针对全局和接口）.....	628
11.6.1.4 配置 ARP 报文限速（针对 Super VLAN 的 VLANIF 接口）.....	629
11.6.1.5 配置 ARP Miss 消息限速（根据源 IP 地址）.....	629
11.6.1.6 配置 ARP Miss 消息限速（针对全局）.....	630
11.6.1.7 配置临时 ARP 表项的老化时间.....	631
11.6.1.8 配置 ARP 表项严格学习.....	632
11.6.1.9 配置基于接口的 ARP 表项限制.....	632
11.6.1.10 检查防 ARP 泛洪攻击配置结果.....	633
11.6.2 配置防 ARP 欺骗攻击.....	634
11.6.2.1 配置 ARP 表项固化.....	634
11.6.2.2 配置动态 ARP 检测.....	635
11.6.2.3 配置 ARP 防网关冲突.....	636
11.6.2.4 配置发送 ARP 免费报文.....	637
11.6.2.5 配置 ARP 报文内 MAC 地址一致性检查.....	637
11.6.2.6 配置 ARP 报文合法性检查.....	638
11.6.2.7 配置 ARP 表项严格学习.....	639
11.6.2.8 配置 DHCP 触发 ARP 学习.....	639
11.6.2.9 检查防 ARP 欺骗攻击配置结果.....	640
11.7 维护 ARP 安全.....	640
11.7.1 监控 ARP 安全运行情况.....	641
11.7.2 清除 ARP 安全统计信息.....	641
11.7.3 配置对潜在的 ARP 攻击行为发送告警.....	641
11.8 ARP 安全配置举例.....	642
11.8.1 配置 ARP 安全综合功能示例.....	642

11.8.2 配置防止 ARP 中间人攻击示例.....	646
11.9 ARP 安全 FAQ.....	649
11.9.1 使能 ARP 网关冲突后，使用某 MAC 发送网关冲突 ARP 报文，再使用该 MAC 发送转发流量为何不通.....	649
11.9.2 用户发送相同源 IP 的 ARP 请求报文，为何有时只能收到 5pps 速率的回应报文.....	649
11.9.3 如何配置防止内网攻击.....	649
12 端口安全配置.....	651
12.1 端口安全简介.....	651
12.2 端口安全原理描述.....	651
12.3 端口安全应用场景.....	652
12.4 端口安全配置注意事项.....	654
12.5 端口安全缺省配置.....	654
12.6 配置端口安全.....	655
12.6.1 配置安全 MAC 功能.....	655
12.6.2 配置 Sticky MAC 功能.....	656
12.7 端口安全配置举例.....	658
12.7.1 配置端口安全示例.....	658
13 DHCP Snooping 配置.....	661
13.1 DHCP Snooping 简介.....	661
13.2 DHCP Snooping 原理描述.....	662
13.2.1 DHCP Snooping 的基本原理.....	662
13.2.2 DHCP Snooping 支持的 Option82 功能.....	663
13.2.3 DHCPv6 Snooping 支持的 LDRA 功能.....	664
13.2.4 DHCPv6 Snooping 支持的 option18 与 option37 功能.....	666
13.3 DHCP Snooping 应用场景.....	666
13.3.1 防止 DHCP Server 仿冒者攻击.....	666
13.3.2 防止仿冒 DHCP 报文攻击.....	667
13.3.3 防止 DHCP Server 服务拒绝攻击.....	668
13.3.4 Option82 的典型应用.....	668
13.3.5 通过 LDRA 功能感知用户位置信息.....	669
13.4 DHCP Snooping 配置注意事项.....	670
13.5 DHCP Snooping 缺省配置.....	671
13.6 配置 DHCP Snooping 的基本功能.....	671
13.6.1 使能 DHCP Snooping 功能.....	672
13.6.2 配置接口信任状态.....	673
13.6.3 （可选）使能 DHCP Snooping 用户位置迁移功能.....	673
13.6.4 （可选）配置 ARP 与 DHCP Snooping 的联动功能.....	674
13.6.5 （可选）配置丢弃 GIADDR 字段非零的 DHCP 报文.....	674
13.6.6 （可选）配置 DHCPv6 Snooping 探测 confirm-client 是否在线功能.....	675
13.6.7 （可选）去使能接口 DHCP Snooping 功能.....	675
13.6.8 检查 DHCP Snooping 基本功能的配置结果.....	676
13.7 配置 DHCP Snooping 的攻击防范功能.....	676

13.7.1 配置防止 DHCP Server 仿冒者攻击.....	677
13.7.2 配置防止仿冒 DHCP 报文攻击.....	677
13.7.3 配置防止 DHCP Server 服务拒绝攻击.....	678
13.7.4 检查 DHCP Snooping 攻击防范功能的配置结果.....	680
13.8 配置在 DHCP 报文中添加 Option82 字段.....	680
13.9 配置通过 LDRA 功能感知用户位置.....	684
13.10 配置在 DHCPv6 报文中添加 Option18 或 Option37 字段.....	685
13.11 维护 DHCP Snooping.....	687
13.11.1 清除 DHCP Snooping 的统计信息.....	687
13.11.2 清除 DHCP Snooping 绑定表.....	687
13.12 DHCP Snooping 配置举例.....	688
13.12.1 配置 DHCP Snooping 的攻击防范功能示例.....	688
13.12.2 配置通过 LDRA 功能感知用户位置示例.....	691
13.13 DHCP Snooping 常见配置错误.....	694
13.13.1 DHCP Snooping 导致用户无法上线.....	694
13.14 DHCP Snooping FAQ.....	695
13.14.1 设备上如果没有 LAN 板，可以实现 DHCP Snooping 功能吗？.....	695
14 IPSPG 配置.....	696
14.1 IPSPG 简介.....	696
14.2 IPSPG 原理描述.....	697
14.2.1 基本原理.....	697
14.2.2 IPSPG 应用在网络中的位置.....	700
14.2.3 IPSPG 与其他相关特性的比较.....	702
14.3 IPSPG 应用场景.....	706
14.4 IPSPG 配置注意事项.....	707
14.5 IPSPG 缺省配置.....	708
14.6 配置 IPSPG.....	708
14.6.1 配置基于静态绑定表的 IPSPG.....	708
14.6.2 配置基于动态绑定表的 IPSPG.....	711
14.7 IPSPG 配置举例.....	713
14.7.1 配置 IPSPG 防止主机仿冒其他主机 IP 地址示例（静态绑定）.....	713
14.7.2 配置 IPSPG 防止主机仿冒其他主机 IP 地址示例（DHCP Snooping 动态绑定）.....	716
14.7.3 配置 IPSPG 限制非法主机访问内网示例（静态绑定）.....	720
14.8 IPSPG 常见配置错误.....	723
14.8.1 接口或 VLAN 上未使能导致 IPSPG 功能不生效.....	723
14.8.2 静态绑定表项错误导致合法主机上不了网.....	724
14.8.3 IPSPG 中未配置上行信任接口导致业务不通.....	725
14.8.4 上行接口使能 IPSPG 导致业务不通.....	726
14.8.5 配置 IP 和 MAC 绑定后，未绑定的主机仍可以上网.....	727
14.8.6 动态环境下未配置 DHCP Snooping 导致 IPSPG 功能不生效.....	728
14.9 IPSPG FAQ.....	728
14.9.1 路由器是否支持一个接口绑定多个 IP 地址.....	728

14.9.2 路由器是否支持一个 MAC 地址绑定多个 IP 地址.....	729
15 URPF 配置.....	730
15.1 URPF 简介.....	730
15.2 URPF 原理描述.....	731
15.3 URPF 应用场景.....	732
15.4 URPF 配置注意事项.....	733
15.5 URPF 缺省配置.....	734
15.6 配置 URPF.....	734
15.6.1 配置接口的 URPF 检查模式.....	734
15.6.2 检查 URPF 配置结果.....	735
15.7 URPF 配置举例.....	735
15.7.1 配置 URPF 功能示例.....	735
16 PKI 配置.....	738
16.1 PKI 简介.....	738
16.2 PKI 原理描述.....	739
16.2.1 PKI 基本概念.....	739
16.2.1.1 加密.....	740
16.2.1.2 数字信封和数字签名.....	742
16.2.1.3 数字证书.....	744
16.2.2 PKI 体系架构.....	747
16.2.3 PKI 工作机制.....	750
16.3 PKI 应用场景.....	753
16.3.1 在 IPSec VPN 中应用.....	753
16.4 PKI 配置注意事项.....	753
16.5 PKI 缺省配置.....	754
16.6 PKI 配置任务概览.....	754
16.7 配置 PKI.....	756
16.7.1 申请本地证书的预配置.....	756
16.7.1.1 配置 PKI 实体信息.....	757
16.7.1.2 配置 RSA/SM2 密钥对.....	758
16.7.1.3 配置为 PKI 实体获取 CA 证书.....	759
16.7.1.3.1 配置为 PKI 实体下载 CA 证书.....	760
16.7.1.3.2 （可选）配置为 PKI 实体安装 CA 证书.....	761
16.7.1.4 检查申请本地证书的预配置的配置结果.....	761
16.7.2 申请和更新本地证书.....	762
16.7.2.1 配置通过 SCEP 协议为 PKI 实体申请和更新本地证书.....	762
16.7.2.2 配置通过 CMPv2 协议为 PKI 实体申请和更新本地证书.....	765
16.7.2.3 配置为 PKI 实体离线申请本地证书.....	769
16.7.2.4 检查申请和更新本地证书的配置结果.....	770
16.7.3 （可选）下载本地证书.....	770
16.7.4 （可选）安装本地证书.....	771
16.7.5 验证 CA 证书和本地证书.....	772

16.7.5.1 配置检查本地证书状态.....	773
16.7.5.2 配置检查 CA 证书和本地证书有效性.....	777
16.7.5.3 检查验证 CA 证书和本地证书的配置结果.....	778
16.7.6 删除本地证书.....	778
16.7.7 配置 PKI 扩展功能.....	778
16.7.7.1 配置获取证书.....	778
16.7.7.2 配置导入和释放对端实体的证书.....	779
16.7.7.3 配置自签名证书或设备本地证书.....	779
16.7.7.4 配置 PKI 加入到指定的 VPN 内.....	780
16.8 维护 PKI.....	780
16.8.1 查看 PKI 信息.....	780
16.8.2 清除 PKI 信息.....	781
16.9 PKI 配置举例.....	781
16.9.1 配置通过 SCEP 协议自动为 PKI 实体申请本地证书示例.....	781
16.9.2 配置通过 CMPv2 协议为 PKI 实体首次申请本地证书示例.....	786
16.9.3 配置为 PKI 实体离线申请本地证书示例.....	792
16.10 PKI 常见配置错误.....	796
16.10.1 获取 CA 证书失败.....	796
16.10.2 获取本地证书失败.....	797
16.11 PKI FAQ.....	798
16.11.1 CA 证书、本地证书和自签名证书的区别？	798
16.11.2 证书支持哪几种格式？	799
16.11.3 如何手工导入证书和 RSA 密钥对？	800
17 SSL 配置.....	802
17.1 SSL 概述.....	802
17.2 SSL 配置注意事项.....	804
17.3 SSL 缺省配置.....	804
17.4 配置服务器型 SSL 策略.....	805
17.5 配置客户端型 SSL 策略.....	807
17.6 维护 SSL.....	809
17.6.1 查看 SSL 连接数的统计信息.....	809
17.6.2 清除 SSL 连接数的统计信息.....	809
17.7 SSL 配置举例.....	810
17.7.1 配置服务器型 SSL 策略示例.....	810
17.7.2 配置客户端型 SSL 策略示例.....	812
18 HTTPS 配置.....	817
18.1 HTTPS 概述.....	817
18.2 HTTPS 配置注意事项.....	818
18.3 配置 HTTPS 服务器.....	818
18.4 HTTPS 配置举例.....	819
18.4.1 配置 HTTPS 服务器示例.....	819

19 Keychain 配置..... 822

19.1 Keychain 简介..... 822

19.2 Keychain 原理描述..... 823

19.2.1 基本概念..... 823

19.2.2 非 TCP 应用程序应用 Keychain 的原理..... 824

19.2.3 TCP 应用程序应用 Keychain 的原理..... 826

19.3 Keychain 应用场景..... 828

19.4 Keychain 配置注意事项..... 829

19.5 配置 Keychain..... 830

19.5.1 创建 Keychain..... 830

19.5.2 配置 key..... 831

19.5.3 配置应用 Keychain..... 833

19.5.4 检查 Keychain 配置结果..... 833

19.6 Keychain 配置举例..... 833

19.6.1 配置 RIP 应用 Keychain 认证示例..... 834

19.6.2 配置 BGP 应用 Keychain 认证示例..... 837

1 AAA 配置

- [1.1 AAA简介](#)
- [1.2 AAA原理描述](#)
- [1.3 AAA应用场景](#)
- [1.4 AAA配置注意事项](#)
- [1.5 AAA缺省配置](#)
- [1.6 AAA配置任务概览](#)
- [1.7 配置采用本地方式进行认证和授权](#)
- [1.8 配置采用RADIUS方式进行认证、授权和计费](#)
- [1.9 配置采用HWTACACS方式进行认证、授权和计费](#)
- [1.10 配置采用HACA方式进行认证](#)
- [1.11 维护AAA](#)
- [1.12 AAA配置举例](#)
- [1.13 AAA FAQ](#)

1.1 AAA 简介

定义

AAA是Authentication（认证）、Authorization（授权）和Accounting（计费）的简称，是网络安全的一种管理机制，提供了认证、授权、计费三种安全功能。

这三种安全功能的具体作用如下：

- 认证：验证用户是否可以获得网络访问权。
- 授权：授权用户可以使用哪些服务。
- 计费：记录用户使用网络资源的情况。

用户可以使用AAA提供的一种或多种安全服务。例如，公司仅仅想让员工在访问某些特定资源的时候进行身份认证，那么网络管理员只要配置认证服务器即可。但是若希望对员工使用网络的情况进行记录，那么还需要配置计费服务器。

如上所述，AAA是一种管理框架，它提供了授权部分用户去访问特定资源，同时可以记录这些用户操作行为的一种安全机制，因其具有良好的可扩展性，并且容易实现用户信息的集中管理而被广泛使用。AAA可以通过多种协议来实现，在实际应用中，最常使用RADIUS协议。

目的

提供对用户进行认证、授权和计费等安全功能，防止非法用户登录设备，增强设备系统安全性。

1.2 AAA 原理描述

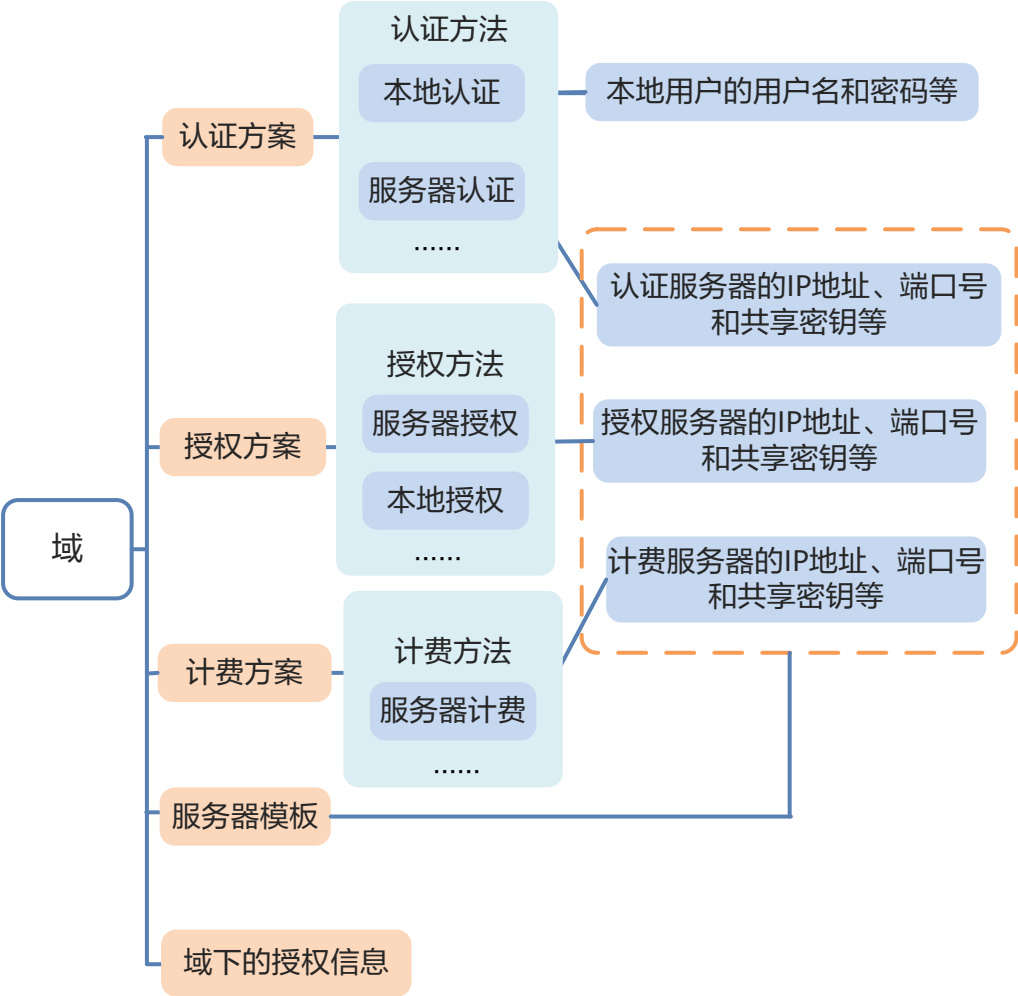
1.2.1 基于域的用户管理

NAS设备对用户的管理是基于域的，每个用户都属于一个域，一个域是由属于同一个域的用户构成的群体。简单地说，用户属于哪个域就使用哪个域下的AAA配置信息。

如[图1-1](#)所示，域统一管理AAA方案、服务器模板和授权等配置信息：

- AAA方案：分为认证方案、授权方案和计费方案，用来定义认证、授权和计费的方法及每种方法的生效顺序，AAA方案的详细介绍请参见[1.2.2 AAA方案](#)。
- 服务器模板：用来配置认证、授权或计费使用的服务器。配置服务器授权时，用户从服务器和域下获取授权信息，详见[图1-2](#)。
如果使用本地认证或授权，需要配置本地用户的相关信息。
- 域下的授权信息：域下还可以配置授权信息。

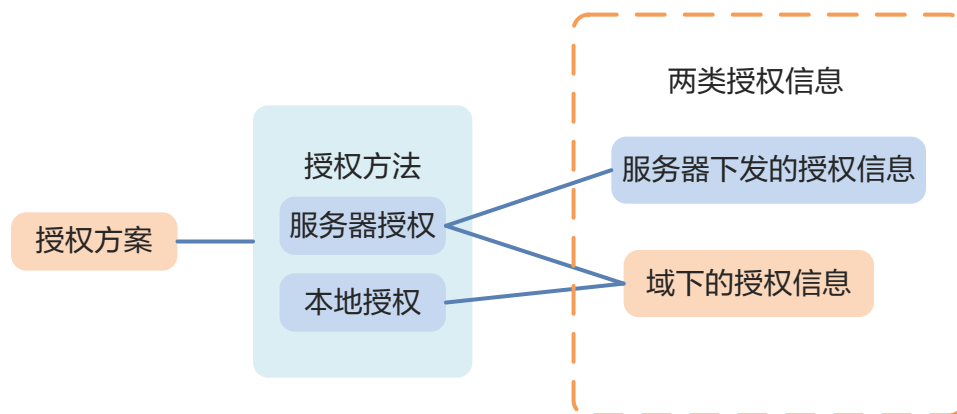
图 1-1 域下的 AAA 配置信息



授权信息分为两类：服务器下发的授权信息和域下的授权信息。用户从何处获取授权与授权方案中配置的授权方法有关。如图1-2所示：

- 授权方法为本地授权时，用户从域下获取授权信息。
- 授权方法为服务器授权时，用户从服务器和域下获取授权信息。域下配置的授权信息比服务器下发的授权信息优先级低，如果两者的授权信息冲突，则服务器下发的授权优先生效；如果两者的授权信息不冲突，则两者的授权信息同时生效。这样处理可以通过域管理进行灵活授权，而不必受限于服务器提供的授权。

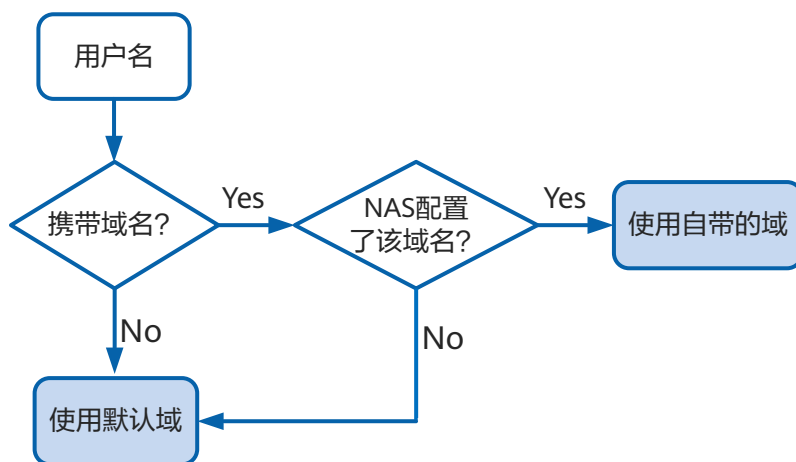
图 1-2 两类授权信息



用户所属的域

如图1-3所示，用户所属的域是由用户登录到NAS设备时提供的用户名决定的，当用户名中没有携带域名或者携带的域名在NAS设备上未配置时，NAS设备无法确认用户所属的域，此时，NAS设备根据用户的类型将用户加入到默认域中。

图 1-3 用户名决定域



如表1-1所示，为了提供更为精细且有差异化的认证、授权、计费服务，AAA将用户划分为管理员用户和接入用户两种类型。NAS设备存在两个全局默认域：全局默认管理域default_admin和全局默认普通域default，分别作为管理员用户和接入用户的全局默认域，两个全局默认域下的缺省配置也不同。

说明

两个全局默认域缺省都绑定了名称为default的计费方案，修改该计费方案会同时影响这两个域的配置。

两个全局默认域均不能删除，只能修改。

表 1-1 全局默认域

用户分类	用户接入方式	使用的全局默认域	全局默认域下的缺省配置		
			认证方案	计费方案	授权方案
管理员用户	又称为Login用户，指可以登录设备的用户。包括通过FTP、HTTP、SSH、Telnet和Console方式登录设备的用户。	default_admin	default（本地认证）	default（不计费）	无
接入用户	包括SSLVPN用户、NAC用户（包括802.1X认证用户、MAC认证用户和Portal认证用户）。	default	radius（本地认证）	default（不计费）	无

用户也可以根据实际需求，灵活定义全局默认域。自定义的全局默认域可以同时被配置成全局默认普通域和全局默认管理域。

通过命令**display aaa configuration**，可以查看设备当前配置的全局默认普通域和全局默认管理域。显示如下：

```
<Huawei> display aaa configuration
Domain Name Delimiter      : @
Domainname parse direction : Left to right
Domainname location        : After-delimiter
Administrator user default domain: default_admin //全局默认管理域
Normal user default domain  : default //全局默认普通域
```

对于某些接入方式，用户最终所属的域可由相应认证模块提供的命令行来指定，以满足一定的用户认证管理策略。例如：NAC接入用户，NAS设备支持基于认证模板配置默认域和强制域，并且可以指定用户类型（802.1X用户、MAC用户或者Portal用户），配置更加灵活。强制域、用户自带域和默认域在不同视图下的优先级从高到低如下所示：

认证模板下指定认证方式的强制域 > 认证模板下的强制域 > 用户自带域 > 认证模板下指定认证方式的默认域 > 认证模板下的默认域 > 全局默认域。比较特殊的是，对于MAC认证用户通过MAC地址段指定的强制域具有最高的优先级，高于认证模板下的配置。

NAS 设备向 RADIUS 服务器发送的用户名格式

说明

- 仅RADIUS认证支持修改用户输入的原始用户名。
- 支持基于RADIUS服务器模板修改用户输入的原始用户名。

NAS设备可以根据RADIUS服务器的要求，配置向RADIUS服务器发送的用户名是否包含域名。缺省情况下，NAS设备向RADIUS服务器发送的用户名为用户输入的原始用户名，不对其进行修改。

通过表1-2中的命令设置NAS设备向RADIUS服务器发送的用户名格式。

以下命令仅会修改发往服务器的RADIUS报文中的用户名格式，EAP报文中的用户名格式不会被修改。由于802.1X认证过程中，RADIUS服务器会检查EAP报文中携带的用户

名与RADIUS服务器上的用户名是否一致，所以，802.1X认证时不能使用命令**radius-server user-name domain-included**和**undo radius-server user-name domain-included**修改用户的原始用户名，以免造成认证失败。

表 1-2 设置 NAS 设备向 RADIUS 服务器发送的用户名格式

命令	用户名格式	用户输入的用户名	NAS设备发送给RADIUS服务器的用户名
radius-server user-name original	用户输入的原始用户名（缺省配置）	user-name@huawei.com	user-name@huawei.com
		user-name	user-name
radius-server user-name domain-included	包含域名	user-name@huawei.com	user-name@huawei.com
		user-name	user-name@default 假设用户使用的默认域为default。
undo radius-server user-name domain-included	不包含域名	user-name@huawei.com	user-name
		user-name	user-name
undo radius-server user-name domain-included except-eap	不包含域名 说明 仅对非EAP认证用户有效	user-name@huawei.com	user-name
		user-name	user-name

1.2.2 AAA 方案

在AAA的具体实现过程中，通过AAA方案来定义一套AAA配置策略。AAA方案是设备上制定的一套认证、授权、计费方法，可根据用户的接入特征以及不同的安全需求组合使用。

1.2.2.1 认证方案

认证方案用来定义用户认证时使用的认证方法以及每种认证方法生效的顺序。认证方案应用到域，与域下的授权方案、计费方案、服务器模板等配置结合，实现对用户进行认证、授权和计费。

设备支持的认证方法

- RADIUS认证：将用户信息配置在RADIUS服务器上，通过RADIUS服务器对用户进行认证。

- HWTACACS认证：将用户信息配置在HWTACACS服务器上，通过HWTACACS服务器对用户进行认证。
- 本地认证：设备作为认证服务器，将用户信息配置在设备上。本地认证的优点是速度快，可以为运营降低成本，缺点是存储信息量受设备硬件条件限制。
- 不认证：对用户非常信任，不对其进行合法性检查，一般情况下不采用这种方式。

认证方法的生效顺序

认证方案中可以指定一种或者多种认证方法：按照配置顺序，NAS设备首先选择第一种认证方法，当前面的认证方法无响应时，后面的认证方法才会被启用；直到某种认证方法有响应或者所有的认证方法遍历完成后均无响应（均无响应时用户认证失败）时，用户身份认证过程将被停止。

说明

仅前一种方法无响应时，NAS设备才尝试使用下一个认证方法。如果某种认证方法回应认证失败，则意味着AAA服务器拒绝用户接入，用户身份认证过程将被停止，并且不会尝试后面的认证方法。

1.2.2.2 授权方案

授权方案用来定义用户授权时使用的授权方法以及每种授权方法生效的顺序。授权方案应用到域，与域下的认证方案、计费方案、服务器模板等配置结合，实现对用户进行认证、授权和计费。

设备支持的授权方法

- HWTACACS授权：由HWTACACS服务器对用户进行授权。
- 本地授权：设备作为授权服务器，根据设备上配置的用户信息进行授权。
- 不授权：不对用户进行授权。
- if-authenticated授权：用户认证通过，则授权通过，否则授权不通过。适用于用户必须认证且认证过程与授权过程可分离的场景。

说明

RADIUS认证与授权结合，不能分离，认证成功授权也成功。采用RADIUS认证时，不需要配置授权方案。

除此之外，对于管理员用户（即Login用户），通常使用“认证+权限级别”的方法控制用户访问设备，提高对设备操作的安全性。其中，认证用来限制对网络设备的访问；权限级别定义用户登录到网络设备后可以执行的命令。该方法的详细介绍请参见《Huawei AR系列 V300R021 配置指南（命令行）-基础配置》中的“通过CLI登录设备配置”。

授权方法的生效顺序

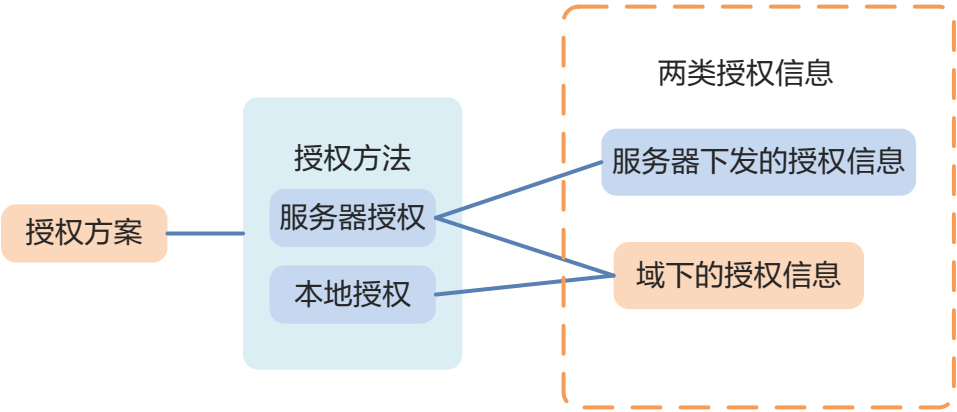
授权方案中可以指定一种或者多种授权方法。指定多种授权方法时，配置顺序决定了每种授权方法生效的顺序，配置在前的授权方法优先生效。当前面的授权方法无响应时，后面的授权方法才会启用。如果前面的授权方法回应授权失败，表示AAA服务器拒绝为用户提供服务。此时，授权结束，后面的授权方法不会被启用。

授权信息

授权信息分为两类：服务器下发的授权信息和域下的授权信息。用户从何处获取授权与授权方案中配置的授权方法有关。如图1-4所示：

- 授权方法为本地授权时，用户从域下获取授权信息。
- 授权方法为服务器授权时，用户从服务器和域下获取授权信息。域下配置的授权信息比服务器下发的授权信息优先级低，如果两者的授权信息冲突，则服务器下发的授权优先生效；如果两者的授权信息不冲突，则两者的授权信息同时生效。这样处理可以通过域管理进行灵活授权，而不必受限于服务器提供的授权。

图 1-4 两类授权信息



服务器常用的授权信息请参见表1-3。域下支持配置的授权信息请参见表1-4。

表 1-3 服务器常用的授权信息

授权信息	说明
ACL编号	服务器下发ACL编号，NAS设备需要配置该ACL编号对应的规则。
ACL规则	服务器直接下发ACL规则，用户能够访问ACL所包括的网络资源。NAS设备上不需要配置对应的ACL。
VLAN	服务器上配置了动态VLAN下发功能，则授权信息中含有下发的VLAN属性，NAS设备在接收到下发的VLAN属性后，会将用户所属的VLAN修改为下发VLAN。 授权下发的VLAN并不改变接口的配置，也不影响接口的配置。但是，授权下发的VLAN的优先级高于用户配置的VLAN，即通过认证后起作用的VLAN是授权下发的VLAN，用户配置的VLAN在用户下线后生效。
用户组	服务器向NAS设备下发用户组名，NAS设备上需要配置对应的组及组内的网络资源。
CAR	服务器下发授权，控制用户接入到NAS设备或者NAS设备到用户的平均速率（CIR）、峰值速率（PIR）、承诺突发尺寸（CBS）和峰值突发尺寸（PBS）。

授权信息	说明
管理员用户级别	服务器下发管理用户（例如Telnet用户）的优先级，有效值范围0～15。授权大于等于16的为无效值。
业务方案	服务器下发业务方案名称，NAS设备上需要配置对应的业务方案及其下的网络授权和策略。
闲置切断	服务器下发闲置切断时间，用户上线后，如果连续无操作或者流量低于某个设置值的时长超过该时间，则断开用户连接。
重认证、强制用户下线	服务器下发为用户提供服务的剩余时长，时间到达后，根据服务器下发的动作对用户重认证或者强制用户下线。

表 1-4 域下支持配置的授权信息

授权参数	说明
VLAN	部署简单，维护成本也较低，由于其控制粒度在VLAN层面，适用于在同一办公室或同一部门所有人员权限相同的场景。 本地授权时，仅需在NAS设备上配置VLAN及VLAN内的网络资源。 用户使用Portal认证或包含Portal认证的混合认证时，不支持为其授权VLAN。 用户获取VLAN授权后，需要手动触发DHCP申请IP地址。
业务方案	业务方案及业务方案所包括的网络资源需要在NAS设备上配置。
用户组	用户组指具有相同角色、相同权限等属性的一组用户（终端）的集合。例如，园区网中可以根据企业部门结构划分研发组、财务组、市场组、访客组等部门用户组，对于不同部门可授予不同安全策略。 用户组及用户组内的网络资源需要在NAS设备上配置。

1.2.2.3 计费方案

计费方案用来定义用户计费时使用的计费方法。计费方案应用到域，与域下的认证方案、授权方案、服务器模板等配置结合，实现对用户进行认证、授权和计费。

设备支持的计费方法

- RADIUS计费：由RADIUS服务器对用户进行计费。
- HWTACACS计费：由HWTACACS服务器对用户进行计费。
- 不计费：不对用户计费。

计费方法的生效顺序

计费方案中只能指定一种计费方法。

从**1.2.4.2 RADIUS报文介绍**中的RADIUS计费报文可以看出，计费报文分为计费请求报文（Accounting-Request）和计费响应报文（Accounting-Response）。设备每发送一个计费请求报文，如果收到服务器回应的计费响应报文则代表计费成功；如果没有收到服务器回应的计费响应报文则代表计费失败。

计费功能使能后，设备会将用户的活动通过计费请求报文（Accounting-Request）发送给AAA服务器，AAA服务器根据报文中的信息对用户进行计费和审计。以RADIUS计费为例，计费请求报文分为三类：

- 计费开始请求报文：用户认证成功开始访问网络资源时，设备向RADIUS服务器发送计费开始请求报文；
- 计费结束请求报文：用户断开连接时（连接也可以由接入服务器断开），设备向服务器发送计费结束请求报文；
- 实时计费请求报文：为减少计费误差、避免计费服务器无法收到计费停止请求报文而继续对该用户计费，可以在设备上配置实时计费功能，此后设备将周期性的向RADIUS服务器发送实时计费请求报文。

正常情况下，设备每发送一个计费请求报文（Accounting-Request），服务器都会回应一个计费响应报文（Accounting-Response）。由于网络故障等原因，设备没有收到对应的计费响应报文时，称之为计费失败。在计费失败时，设备根据计费请求报文的类型对用户能否在线做出相应的处理，具体如下：

- 开始计费失败：默认使用户下线。
- 实时计费失败：默认允许用户在线。
- 结束计费失败：重传计费结束请求报文。

1.2.3 本地认证和授权

本地 AAA 服务器

设备作为AAA服务器时被称为本地AAA服务器，本地AAA服务器支持对用户进行认证和授权，不支持对用户进行计费。

与远端AAA服务器相似，本地AAA服务器需要配置本地用户的用户名、密码、授权信息等。使用本地AAA服务器进行认证和授权比远端AAA服务器的速度快，可以降低运营成本，但是存储信息量受设备硬件条件限制。

本地用户的密码策略

密码长度和密码复杂度

管理员在创建本地用户时，设备命令行已经对本地用户密码的长度和复杂度做了控制。其中，复杂度检查建议密码至少包含小写字母、大写字母、数字、特殊字符这四种形式中的两种，同时密码长度不小于8个字符。

密码有效期

开启本地管理员密码策略后，本地管理员用户可以设置密码有效期，有效期默认为90天、支持修改。

如果密码已经过期，有用户继续通过此密码登录设备时，设备提示用户密码已过期、是否修改密码，并根据用户的选择进行不同的处理：

- 如果用户选择修改，则用户需要按照先后顺序输入旧密码、新密码、确认新密码。只有旧密码正确，新密码和确认新密码输入一致并符合要求（密码长度、复杂度等）时，密码才能修改成功。

- 如果用户选择不修改或者修改失败，则不允许用户登录。

同时，设备还支持密码过期前提醒功能。当用户登录设备时，设备会判断该用户的密码距离过期的时间是否在提醒时间范围内。如果在提醒时间范围内，设备会提示该密码还有多久过期，并询问用户是否修改密码：

- 如果用户选择修改，则记录新的密码以及修改密码的时间。
- 如果用户选择不修改或者修改失败，则在密码未过期的情况下仍可以正常登录。

密码修改策略

修改密码时不建议使用以前使用过的密码，默认新密码不得与前5次使用过的密码重复。

本地管理员可以修改同级别或者低级别本地用户的密码。

1.2.4 RADIUS 认证、授权和计费

1.2.4.1 RADIUS 概述

AAA可以通过多种协议来实现，在实际应用中，最常使用RADIUS协议。

RADIUS是一种分布式的、客户端/服务器结构的信息交互协议，能保护网络不受未经授权访问的干扰，常应用在既要求较高安全性、又允许远程用户访问的各种网络环境中。该协议定义了基于UDP（User Datagram Protocol）的RADIUS报文格式及其传输机制，并规定目的UDP端口号1812、1813分别作为默认认证、计费端口号。

RADIUS最初仅是针对拨号用户的AAA协议，后来随着用户接入方式的多样化发展，RADIUS也适应多种用户接入方式，如以太网接入等。它通过认证授权来提供接入服务，通过计费来收集、记录用户对网络资源的使用。

RADIUS协议的主要特征如下：

- 客户端/服务器模式
- 安全的消息交互机制
- 良好的扩展性

客户端/服务器模式

- RADIUS客户端

一般位于网络接入服务器NAS（Network Access Server）上，可以遍布整个网络，负责传输用户信息到指定的RADIUS服务器，然后根据从服务器返回的信息进行相应处理（如接受/拒绝用户接入）。

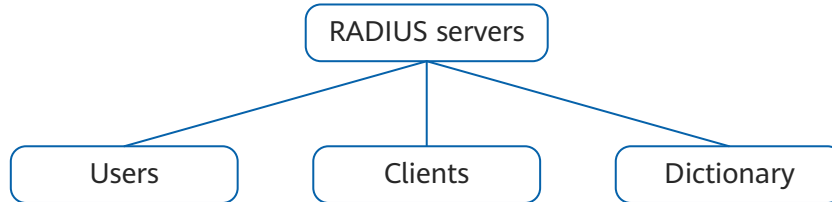
设备作为RADIUS协议的客户端，实现以下功能：

- 支持标准RADIUS协议及扩充属性，包括RFC2865、RFC2866。
- 支持华为RADIUS扩展属性。
- 对RADIUS服务器状态探测功能。
- 计费结束请求报文的本地缓存重传功能。
- RADIUS服务器主备或负载分担功能。

- RADIUS服务器

一般运行在中心计算机或工作站上，维护相关的用户认证和网络服务访问信息，负责接收用户连接请求并认证用户，然后给客户端返回所有需要的信息（如接受/拒绝认证请求）。RADIUS服务器通常要维护三个数据库，如图1-5所示。

图 1-5 RADIUS 服务器的组成



- Users: 用于存储用户信息（如用户名、密码以及使用的协议、IP地址等配置信息）。
- Clients: 用于存储RADIUS客户端的信息（如共享密钥、IP地址等）。
- Dictionary: 用于存储RADIUS协议中的属性和属性值含义的信息。

安全的消息交互机制

RADIUS客户端和RADIUS服务器之间认证消息的交互是通过共享密钥的参与来完成的。共享密钥是一个带外传输的、客户端和服务端都知道的字符串，不需要单独进行网络传输。RADIUS报文中有一个16字节的验证字段，它包含了对整个报文的数字签名数据，该签名数据是在共享密钥的参与下利用MD5算法计算得出。收到RADIUS报文的一方要验证该签名的正确性，如果报文的签名不正确，则丢弃它。通过这种机制，保证了RADIUS客户端和RADIUS服务器之间信息交互的安全性。另外，为防止用户密码在不安全的网络上传递时被窃取，在RADIUS报文传输过程中还利用共享密钥对用户密码进行了加密。

良好的扩展性

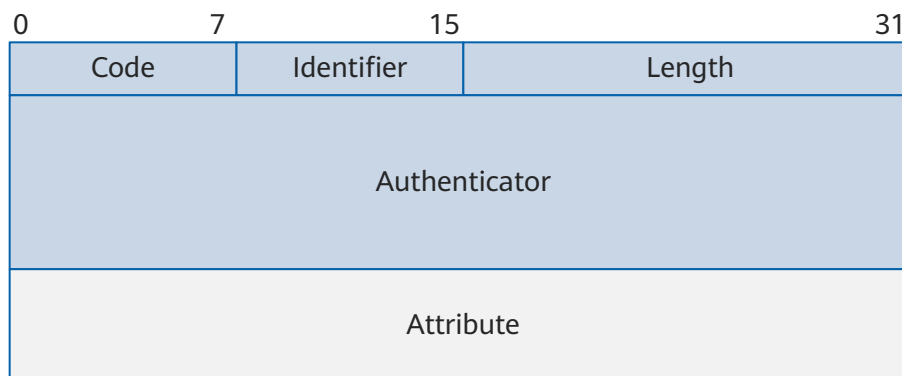
RADIUS报文是由报文头和一定数目的属性（Attribute）构成，新属性的加入不会破坏协议的原有实现。

1.2.4.2 RADIUS 报文介绍

RADIUS 报文格式

RADIUS协议是基于UDP协议的，RADIUS报文格式如图1-6所示。

图 1-6 RADIUS 报文格式



各字段的解释如下：

- Code：长度为1个字节，用来说明RADIUS报文的类型。不同RADIUS报文的Code值不相同。例如，Code为1时表示Access-Request报文，Code为2时表示Access-Accept报文。
- Identifier：长度为1个字节，用来匹配请求报文和响应报文，以及检测在一段时间内重发的请求报文。RADIUS客户端发送请求报文后，RADIUS服务器返回的响应报文中的Identifier值应与请求报文中的Identifier值相同。
- Length：长度为2个字节，用来指定RADIUS报文的长度。超过Length取值的字节将作为填充字符而忽略。如果接收到的报文的实际长度小于Length的取值，则该报文会被丢弃。
- Authenticator：长度为16个字节，用来验证RADIUS服务器的响应报文，同时还用于用户密码的加密。
- Attribute：即RADIUS属性字段，长度不定，为报文的内容主体，用来携带专门的认证、授权和计费信息，提供请求和响应报文的配置细节。Attribute可以包括多个RADIUS属性，每一个RADIUS属性都采用（Type、Length、Value）三元组的结构来表示，具体请参见[1.2.4.8 RADIUS属性](#)。
 - 类型（Type）：长度为1个字节，取值为1～255，用于表示RADIUS属性的编号。
 - 长度（Length）：长度为1个字节，表示该RADIUS属性（包括类型、长度和属性值）的长度，单位为字节。
 - 属性值（Value）：最大长度为253字节，表示该RADIUS属性的信息，其格式和内容由类型和长度决定。

RADIUS 报文类型

目前RADIUS定义了十六种报文类型，其中认证报文类型如[表1-5](#)所示，计费报文类型如[表1-6](#)所示，RADIUS CoA/DM报文请参见[1.2.4.7 RADIUS CoA/DM](#)。

表 1-5 RADIUS 认证报文

报文名称	说明
Access-Request	认证请求报文，是RADIUS报文交互过程中的第一个报文，用来携带用户的认证信息（例如：用户名、密码等）。认证请求报文由RADIUS客户端发送给RADIUS服务器，RADIUS服务器根据该报文中携带的用户信息判断是否允许接入。
Access-Accept	认证接受报文，是RADIUS服务器对RADIUS客户端发送的Access-Request报文的接受响应报文。如果Access-Request报文中的所有属性都可以接受（即认证通过），则发送该类型报文。RADIUS客户端收到此报文后，用户才能认证通过并被赋予相应的权限。
Access-Reject	认证拒绝报文，是RADIUS服务器对RADIUS客户端的Access-Request报文的拒绝响应报文。如果Access-Request报文中的任何一个属性不可接受（即认证失败），则RADIUS服务器返回Access-Reject报文，用户认证失败。
Access-Challenge	认证挑战报文。EAP中继认证时，RADIUS服务器接收到Access-Request报文中携带的用户名信息后，会随机生成一个MD5挑战字，同时将此挑战字通过Access-Challenge报文发送给用户。用户使用该挑战字对用户密码进行加密处理后，将新的用户密码信息通过Access-Request报文发送给RADIUS服务器。RADIUS服务器将收到的已加密的密码信息和本地经过加密运算后的密码信息进行对比，如果相同，则该用户为合法用户。

表 1-6 RADIUS 计费报文

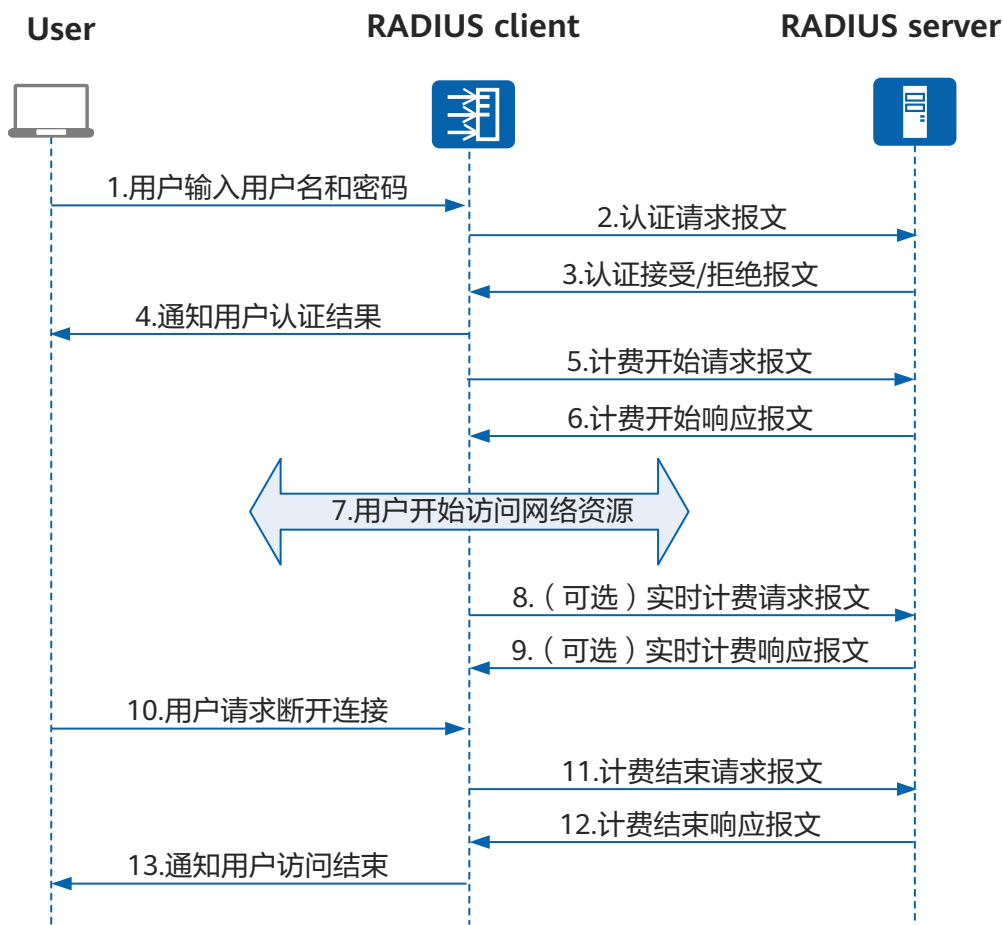
报文名称	说明
Accounting-Request(Start)	计费开始请求报文。如果RADIUS客户端使用RADIUS模式进行计费，RADIUS客户端会在用户开始访问网络资源时，向RADIUS服务器发送计费开始请求报文。
Accounting-Response(Start)	计费开始响应报文。RADIUS服务器接收并成功记录计费开始请求报文后，需要回应一个计费开始响应报文。
Accounting-Request(Interim-update)	实时计费请求报文。为避免RADIUS服务器无法收到计费结束请求报文而继续对该用户计费，可以在RADIUS客户端上配置实时计费功能。RADIUS客户端定时向RADIUS服务器发送实时计费请求报文，减少计费误差。
Accounting-Response(Interim-update)	实时计费响应报文。RADIUS服务器接收并成功记录实时计费请求报文后，需要回应一个实时计费响应报文。
Accounting-Request(Stop)	计费结束请求报文。当用户断开连接时（连接也可以由NAS断开），RADIUS客户端向RADIUS服务器发送计费结束请求报文，其中包括用户上网所使用的网络资源的统计信息（上网时长、进/出的字节数等），请求RADIUS服务器停止计费。

报文名称	说明
Accounting-Response(Stop)	计费结束响应报文。RADIUS服务器接收计费停止请求报文后，需要回应一个计费停止响应报文。

1.2.4.3 RADIUS 认证、授权、计费流程

设备作为RADIUS客户端，负责收集用户信息（例如：用户名、密码等），并将这些信息发送到RADIUS服务器。RADIUS服务器则根据这些信息完成用户身份认证以及认证通过后的用户授权和计费。用户、RADIUS客户端和RADIUS服务器之间的交互流程如图1-7所示。

图 1-7 RADIUS 认证、授权和计费的交互流程



1. 当用户接入网络时，用户发起连接请求，向RADIUS客户端（即设备）发送用户名和密码。
2. RADIUS客户端向RADIUS服务器发送包含用户名和密码信息的认证请求报文。
3. RADIUS服务器对用户身份的合法性进行检验：
 - 如果用户身份合法，RADIUS服务器向RADIUS客户端返回认证接受报文，允许用户进行下一步动作。由于RADIUS协议合并了认证和授权的过程，因此认证接受报文中也包含了用户的授权信息。

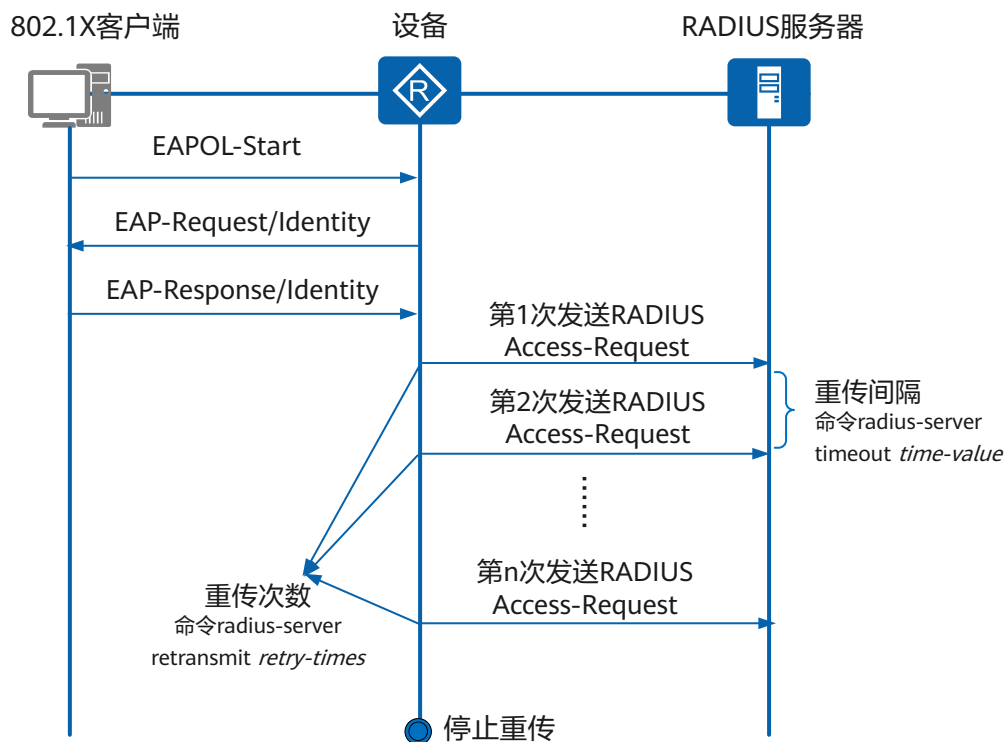
- 如果用户身份不合法，RADIUS服务器向RADIUS客户端返回认证拒绝报文，拒绝用户访问接入网络。
- 4. RADIUS客户端通知用户认证是否成功。
- 5. RADIUS客户端根据接收到的认证结果接入/拒绝用户。如果允许用户接入，则RADIUS客户端向RADIUS服务器发送计费开始请求报文。
- 6. RADIUS服务器返回计费开始响应报文，并开始计费。
- 7. 用户开始访问网络资源。
- 8. （可选）在使能实时计费功能的情况下，RADIUS客户端会定时向RADIUS服务器发送实时计费请求报文，避免因付费用户异常下线导致的不合理计费。
- 9. （可选）RADIUS服务器返回实时计费响应报文，并实时计费。
- 10. 用户发起下线请求，请求停止访问网络资源。
- 11. RADIUS客户端向RADIUS服务器提交计费结束请求报文。
- 12. RADIUS服务器返回计费结束响应报文，并停止计费。
- 13. RADIUS客户端通知用户访问结束，用户结束访问网络资源。

1.2.4.4 RADIUS 报文重传机制

用户认证过程中，设备会发送认证请求报文到RADIUS服务器。为避免由于网络故障、时延等原因导致设备无法收到服务器的回应报文，设备在发送认证请求报文到服务器时具有超时重传超时机制，重传次数和重传间隔通过定时器进行控制。

如图1-8所示，以802.1X认证、客户端主动发起认证为例，设备收到包含客户端用户名信息的EAP报文（EAP-Response/Identity）之后，将EAP报文封装在RADIUS认证请求报文（RADIUS Access-Request）中发送给RADIUS服务器处理，同时开启重传定时器。重传定时器由重传间隔时间和重传次数构成，如果达到重传间隔时间，设备未收到RADIUS服务器的回应报文，会再次发送认证请求报文。

图 1-8 RADIUS 认证报文重传流程图



满足以下任意一个条件，设备停止重传：

- 收到RADIUS服务器的回应报文。收到RADIUS服务器的回应报文后，设备会停止重传，此时设备标记RADIUS服务器的状态为Up。
- 探测到RADIUS服务器的状态为Down。设备将RADIUS服务器的状态置为Down后：
 - 如果达到最大重传次数，则停止重传，RADIUS服务器的状态为Down。
 - 如果还没有达到最大重传次数，设备会再重传一次认证请求报文到RADIUS服务器。相当于给状态为Down的服务器一次机会。如果收到RADIUS服务器的回应报文，停止重传，并将RADIUS服务器的状态恢复为Up；如果未收到RADIUS服务器的回应报文，也停止重传，RADIUS服务器的状态为Down。
- 达到最大重传次数。达到最大重传次数后，设备会停止重传，此时：
 - 如果收到RADIUS服务器的回应报文，此时设备标记RADIUS服务器的状态为Up。
 - 如果已经探测到RADIUS服务器的状态为Down，设备将服务器的状态置为Down。
 - 如果没收到RADIUS服务器的回应报文也没有探测到服务器的状态为Down，此时，设备不会切换服务器的状态，服务器实际上没有响应。

说明

服务器无响应不等同于Down状态，只有满足置Down的条件，设备才会将服务器标记为Down状态。

RADIUS服务器的状态介绍和置Down的条件请参见[1.2.4.6 RADIUS服务器状态探测](#)。

RADIUS报文重传是针对一个服务器而言的，如果RADIUS服务器模板中配置了多个服务器，整体重传时间取决于重传间隔、重传次数、RADIUS服务器的状态、服务器的个数以及选择服务器的算法。

定时器由以下命令设置：

命令	说明
radius-server retransmit <i>retry-times</i>	重传次数，默认值为5。
radius-server timeout <i>time-value</i>	重传间隔，默认值为2秒。

1.2.4.5 RADIUS 服务器选择机制

大型企业网络中通常会部署多台RADIUS服务器，这样做的目的—是为了在一台服务器故障的情况下，不会影响用户接入；二是为了在大量用户接入时，多个服务器之间能够负载均衡，单个服务器的资源不会被耗尽。当RADIUS服务器模板中配置了多个服务器，设备在向服务器发送报文时，根据命令行的配置通过以下其中一种机制选择RADIUS服务器：

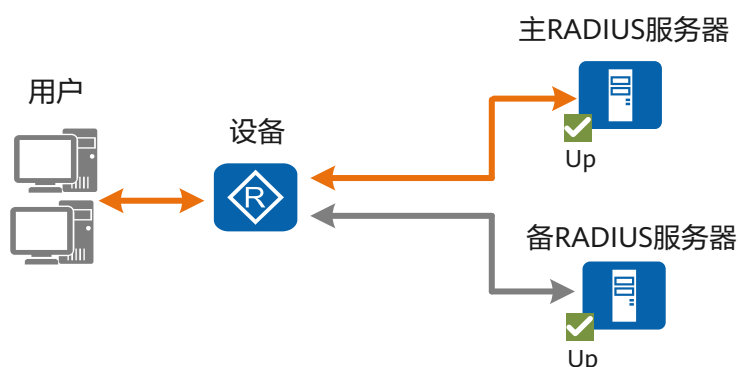
- RADIUS服务器主备算法（缺省配置）
- RADIUS服务器负载均衡算法

另外，RADIUS服务器的运算法则可以配置为基于单个用户的也可以配置为基于报文的。如果配置为基于单个用户的运算法则，认证阶段会保存认证服务器的信息，如果认证服务器同时也是计费服务器，则计费阶段优先向该服务器发送计费请求；如果配置为基于报文的运算法则，认证阶段不会保存认证服务器的信息，在计费阶段会重新选择计费服务器，可能存在同一个用户的认证和计费不在同一个服务器上的问题。

RADIUS 服务器主备算法

主备顺序根据配置RADIUS认证服务器或RADIUS计费服务器时的权重决定，权重值较大者为主，如果权重值相同，则先配置的服务器为主。如图1-9所示，在所有状态为Up的服务器中，优先向主服务器发送认证或计费报文，如果主服务器没有回应，则向备服务器发送。

图 1-9 RADIUS 服务器主备算法示意图

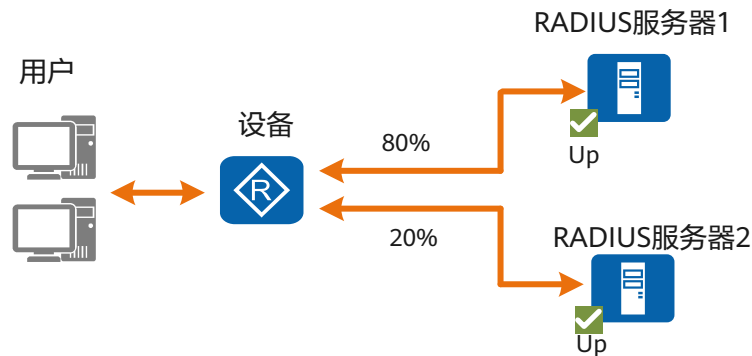


RADIUS 服务器负载均衡算法

选择负载均衡算法后，设备在向服务器发送认证或计费报文时，会根据配置RADIUS认证服务器或RADIUS计费服务器时的权重来分配报文发送的服务器。如图1-10所示，

RADIUS服务器1的状态为Up、权重为80，RADIUS服务器2的状态为Up、权重为20。则设备向RADIUS服务器1发送报文的概率为 $80 / (80 + 20) = 80\%$ ，设备向RADIUS服务器2发送报文的概率 $20 / (80 + 20) = 20\%$ 。

图 1-10 RADIUS 服务器负载均衡算法示意图



如果设备在发送报文的过程中，所有状态为Up的服务器均没有回应，此后，设备在原先为Down状态的服务器（此前没有向这部分服务器发送认证或计费报文）中，按照权重值，再发送一次报文。如果设备没有收到任何服务器的回应报文，则跳转到备份认证方式，比如本地认证。备份方式需要在认证方案中配置，如果未配置，则本次认证流程结束。

1.2.4.6 RADIUS 服务器状态探测

RADIUS服务器的可用性和可维护性为用户接入认证的基本条件，当设备与RADIUS服务器之间无法通信时，RADIUS服务器不能对用户进行认证和授权。为了解决该问题，设备支持在RADIUS服务器Down时的用户逃生功能，即RADIUS服务器Down后，用户无法获取服务器授权时，仍能够具有一定的网络访问权限。

但是，RADIUS服务器Down时的用户逃生功能必须在设备将RADIUS服务器的状态标记为Down后才能启用。如果RADIUS服务器的状态没有标记为Down、设备又不能与RADIUS服务器正常通信，这会导致用户既获取不到服务器授权也不能进行逃生，进而造成用户没有任何网络访问权限。所以，设备必须及时感知到RADIUS服务器的状态，在RADIUS服务器状态为Down时，使用户能够获取逃生权限；在RADIUS服务器状态恢复Up后，用户退出逃生权限，进行重认证。

说明

Accounting报文检测机制与Request报文检测机制一致。

本节介绍的内容包括：

- [RADIUS服务器的状态介绍](#)
- [将RADIUS服务器的状态标记为Down的条件](#)
- [自动探测](#)
- [将RADIUS服务器标记为Down后的处理](#)

RADIUS 服务器的状态

设备将RADIUS服务器的状态分为三种，三种状态的含义及出现的场景如下表所示。

状态	RADIUS服务器是否可用	出现该状态的场景
Up	RADIUS服务器可用	• RADIUS服务器的初始状态 • 设备收到RADIUS服务器的报文
Down	RADIUS服务器不可用	满足将RADIUS服务器的状态标记为Down的条件
Force-up （强制Up）	在没有可用的RADIUS服务器时，会选择Force-up状态的服务器	dead-time 定时器超时

RADIUS服务器的初始状态被标记为Up。在收到RADIUS认证请求报文、并且满足将RADIUS服务器的状态标记为Down的条件时，RADIUS服务器的状态被切换为Down。触发状态切换的RADIUS认证请求报文可以是用户认证过程中发送的，也可以是管理员构造的，比如执行**test-aaa**命令时发送的测试报文或者自动探测时发送的探测报文。

以下几种情形下，设备会将RADIUS服务器的状态由Down切换为Up或者Force-up：

- **dead-time**定时器超时，将RADIUS服务器的状态由Down切换为Force-up：设备在将RADIUS服务器的状态标记为Down后就会启动**dead-time**定时器，该定时器定义了Down状态可持续的时长。定时器超时后，设备将服务器的状态标记为Force-up。之后，如果有新用户需要通过RADIUS方式进行认证，在没有可用的RADIUS服务器的情况下，设备会尝试和Force-up状态的服务器重新建立连接。
- 设备收到RADIUS服务器的报文，将RADIUS服务器的状态由Down切换为Up。例如，配置自动探测后，设备收到RADIUS服务器的响应报文。

将 RADIUS 服务器的状态标记为 Down 的条件

能否将一个RADIUS服务器的状态标记为Down，与以下因素有关：

- RADIUS服务器最大无响应时长（max-unresponsive-interval的取值）
- RADIUS请求报文发送的次数
- RADIUS请求报文发送的时间间隔
- RADIUS服务器的探测周期
- RADIUS服务器探测周期循环次数
- RADIUS服务器在每个探测周期内连续无响应最大次数

将RADIUS服务器的状态标记为Down的条件分为两种，只要满足其中一种，RADIUS服务器的状态就会被标记为Down。[图1-11](#)为将RADIUS服务器的状态标记为Down的逻辑流程图，以探测周期循环两次为例：

- 在RADIUS服务器状态探测过程中，将RADIUS服务器标记为Down状态。
系统启动后，RADIUS服务器状态探测定时器开始运行。从设备发送第一个RADIUS认证请求报文开始计算，如果设备一直没有收到RADIUS服务器的报文，并且在一个探测周期内满足条件：未收到RADIUS服务器报文的次数（n）大于或等于连续无响应的最大次数（dead-count），则记录一次通讯中断。在持续没有收到RADIUS服务器报文的情况下，探测周期循环几次，就在第几次记录通讯中断时将RADIUS服务器标记为Down。

说明

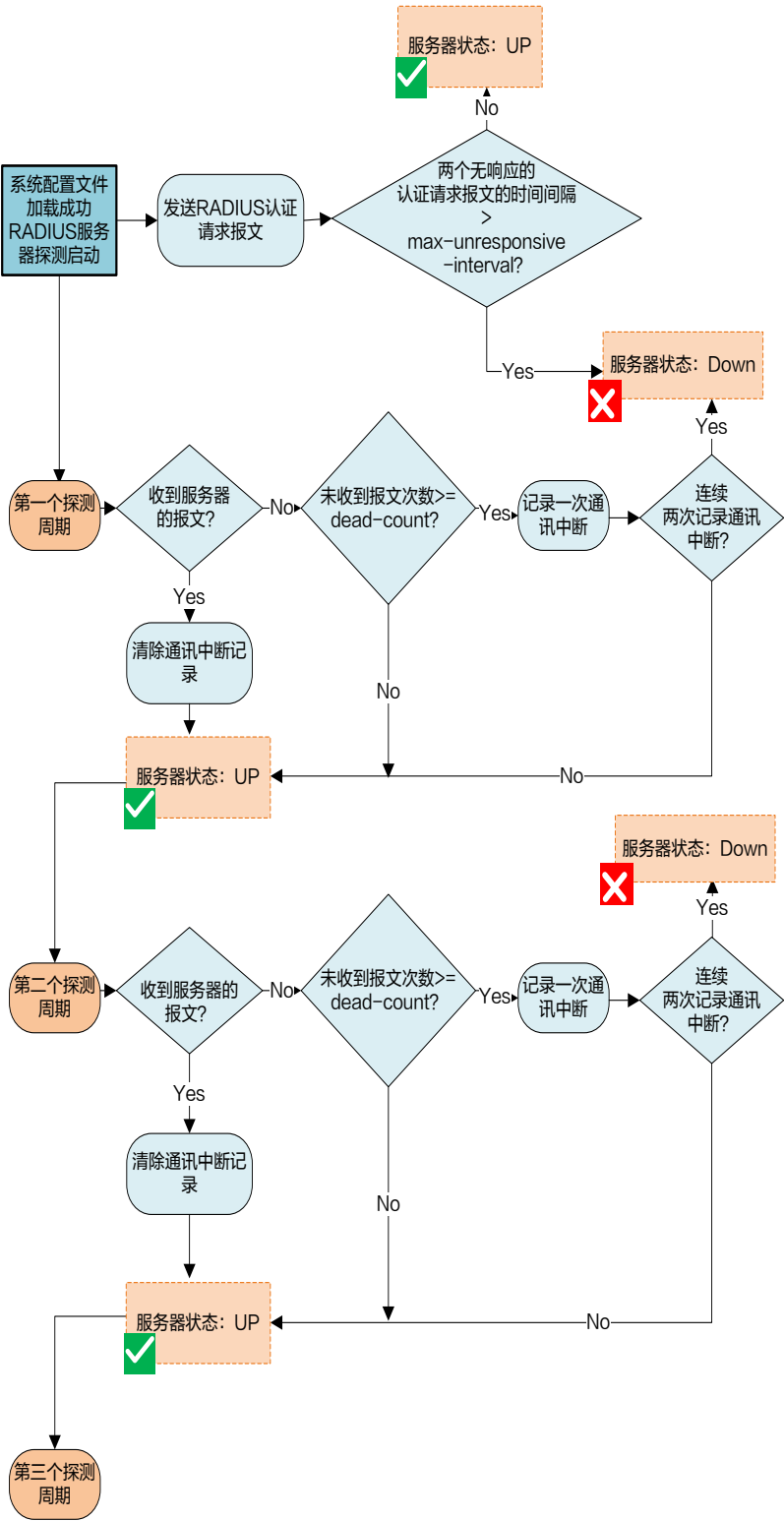
如果某个探测周期未记录通讯中断，则清除之前所有的通讯中断的记录。

- 将长时间无响应的RADIUS服务器标记为Down状态。

在用户接入频率较低、设备收到用户认证请求报文较少、RADIUS服务器状态探测过程中将RADIUS服务器标记为Down的条件无法满足的情况下，连续两个无响应的认证请求报文的时间间隔大于**max-unresponsive-interval**时，RADIUS服务器被标记为Down，此机制能够确保用户获取逃生授权。

如果RADIUS服务器模板中配置了多个服务器，整体状态探测的时间与服务器的个数以及选择服务器的算法有关。当用户终端使用客户端软件进行认证时，如果终端客户端软件的超时等待时间小于所有整体状态探测时间的总和，可能导致终端客户端软件反复拨号而无法接入网络；另外如果配置了用户逃生，为了使用户能够正常加入逃生权限，也需要整体状态探测时间的总和小于终端客户端软件的超时等待时间。

图 1-11 将 RADIUS 服务器的状态标记为 Down 的逻辑流程图



相关命令请参见下表。

命令	说明
radius-server { dead-interval <i>dead-interval</i> dead-count <i>dead-count</i> detect-cycle <i>detect-cycle</i> }	在RADIUS服务器状态探测过程中，将RADIUS服务器的状态标记为Down的条件。 • dead-interval <i>dead-interval</i>: 探测周期，默认值为5秒。 • dead-count <i>dead-count</i>: 连续无响应的最大次数，默认值为2次。 • detect-cycle <i>detect-cycle</i>: 探测周期循环次数，默认为2个周期。
radius-server max-unresponsive-interval <i>interval</i>	RADIUS服务器无响应的最大时长。默认为300秒。 连续两个无响应的认证请求报文的时间间隔大于 max-unresponsive-interval 时，则将RADIUS服务器的状态标记为Down。
radius-server dead-time <i>dead-time</i>	RADIUS服务器Down状态可持续的时长。 <i>dead-time</i> : 设备将RADIUS服务器的状态标记为Down后，等待设置的 <i>dead-time</i> 时间，设备会将服务器的状态设置Force-up。默认值为5分钟。

自动探测

RADIUS服务器的状态被标记为Down后，通过自动探测功能可以检测RADIUS服务器的可达性。

自动探测功能需要手动开启。开启自动状态探测功能只需在设备的RADIUS服务器模板视图下配置自动探测用户名和密码，在RADIUS服务器上不需要配置此自动探测用户名和密码。认证无需成功，设备能收到认证失败响应报文就能证明RADIUS服务器是正常工作的。

开启自动状态探测功能后，按照RADIUS服务器状态的差异，自动探测可以分为以下三种情况：

服务器的状态	是否支持自动探测	何时发送自动探测报文	服务器状态切换的条件
Down状态	缺省支持	自动探测周期过后发送	在探测报文的超时等待时间内，如果设备收到了RADIUS服务器的报文，会将RADIUS服务器的状态标记为Up；反之，则保持RADIUS服务器的状态为Down。

服务器的状态	是否支持自动探测	何时发送自动探测报文	服务器状态切换的条件
Up状态	通过命令行 radius-server detect-server up-server interval 开启	自动探测周期过后发送	满足将RADIUS服务器的状态标记为Down的条件，则将RADIUS服务器的状态标记为Down；反之，则保持RADIUS服务器的状态为Up。
Force-up状态	缺省支持	立即发送	在超时等待时间内，如果收到RADIUS服务器的报文，设备会将RADIUS服务器的状态标记为Up；反之，则将RADIUS服务器的状态标记为Down。

 说明

在大型企业网络中，不建议开启对Up状态的RADIUS服务器进行自动探测的功能。这是由于如果多个NAS设备均开启该功能，RADIUS服务器在处理用户认证请求报文的同时还会收到大量周期性的探测报文，会降低RADIUS服务器的处理性能。

配置自动探测功能（命令**radius-server testuser**）后，**dead-time**定时器（命令**radius-server dead-time**）不生效。

自动探测相关命令请参见下表。

命令	说明
radius-server testuser username <i>user-name</i> password cipher <i>password</i>	开启自动探测功能： <i>user-name</i>: 自动探测用户名。 <i>password</i>: 自动探测用户密码。
radius-server detect-server interval <i>interval</i>	状态为Down的RADIUS服务器的自动探测周期，默认为60秒。
radius-server detect-server up-server interval <i>interval</i>	开启状态为Up的RADIUS服务器的自动探测功能并配置自动探测周期。探测周期默认为0秒，即不对状态为Up的RADIUS服务器进行自动探测。
radius-server detect-server timeout <i>time-value</i>	自动探测报文的超时等待时间，默认为3秒。

将 RADIUS 服务器标记为 Down 后的处理

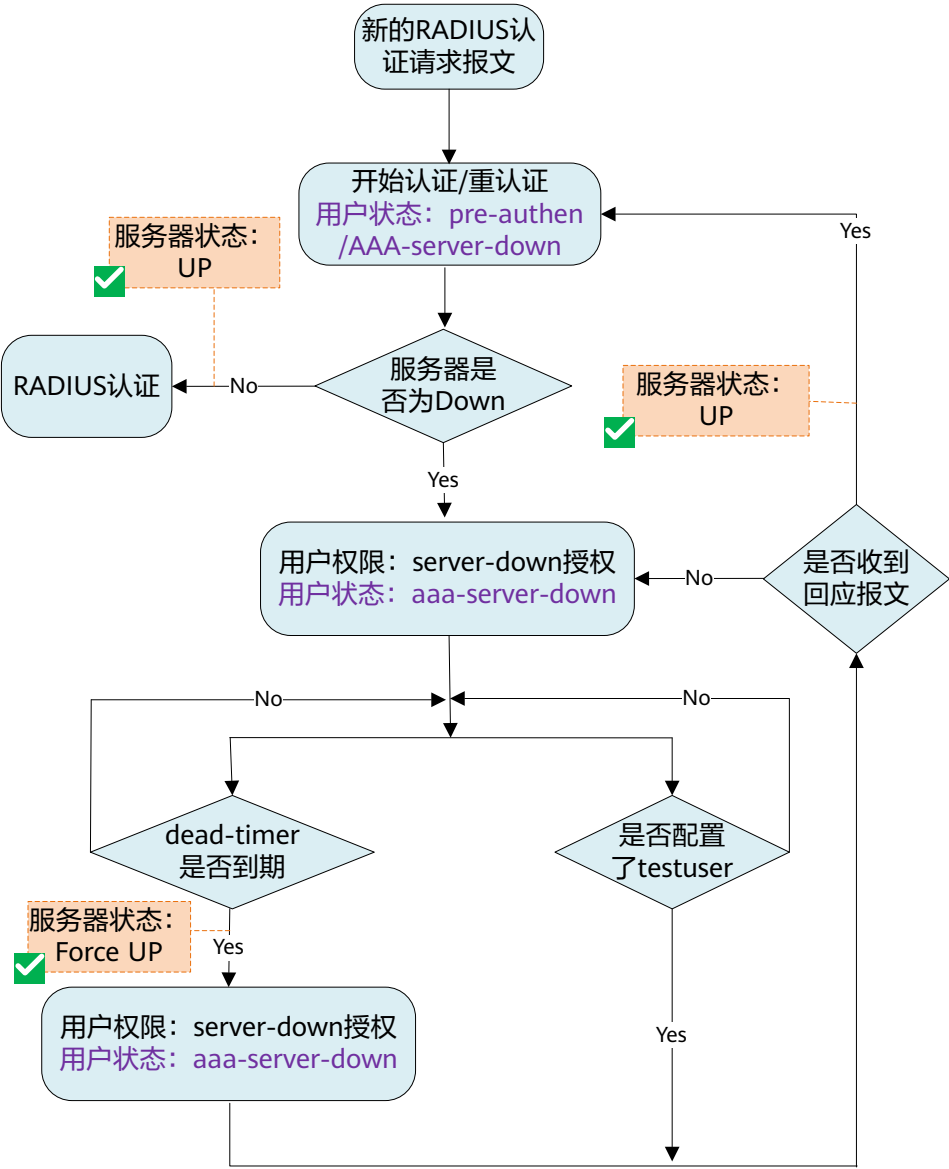
设备将RADIUS服务器的状态标记为Down之后，通过配置逃生功能，使用户能够进入逃生授权。设备探测到RADIUS服务器状态恢复为Up后，通过配置重认证功能，使用户重认证获取RADIUS服务器授权，如图1-12所示。

说明

RADIUS服务器的状态恢复为Up后，对于802.1X认证用户和MAC认证用户，用户会退出逃生授权并进行重认证；对于Portal认证用户，用户会进入预连接授权，在用户访问网络资源时，才会触发重定向到Portal服务器进行认证。

配置自动探测功能（命令radius-server testuser）后，dead-time定时器（命令radius-server dead-time）不生效。

图 1-12 将 RADIUS 服务器标记为 Down 后的处理



RADIUS服务器Down时逃生权限的配置命令以及重认证功能相关命令如下表所示。

命令	说明
authentication event authen-server-down action authorize { vlan <i>vlan-id</i> service-scheme <i>service-scheme-name</i> } [response-fail]	配置RADIUS服务器Down时的逃生功能。
authentication event authen-server-up action re-authen	配置RADIUS服务器恢复为Up时，设备对逃生状态的用户进行重认证。

1.2.4.7 RADIUS CoA/DM

设备支持RADIUS CoA/DM功能，提供一种动态修改在线用户权限或者强制用户下线的机制。本节介绍的内容包括：

- [RADIUS CoA/DM报文](#)
- [交互流程](#)
- [会话标志](#)
- [错误码说明](#)

RADIUS CoA/DM 报文

CoA/DM报文类型如[表1-7](#)所示。

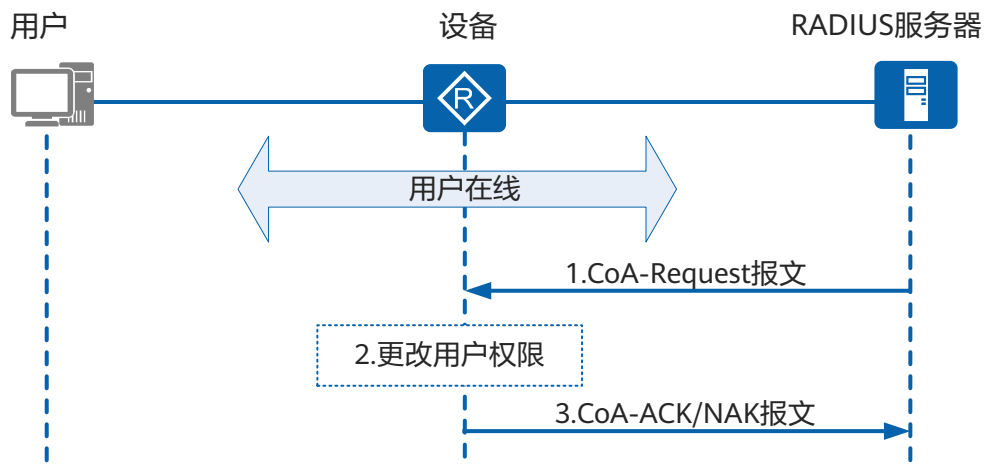
表 1-7 RADIUS CoA/DM 报文

报文名称	说明
CoA-Request	动态授权请求报文。当管理员需要更改某个在线用户的权限时（例如，管理员不希望用户访问某个网站），可以通过RADIUS服务器发送一个动态授权请求报文给RADIUS客户端，使RADIUS客户端修改在线用户的权限。
CoA-ACK	动态授权请求接受报文。如果RADIUS客户端成功更改了用户的权限，则RADIUS客户端回应动态授权请求接受报文给RADIUS服务器。
CoA-NAK	动态授权请求拒绝报文。如果RADIUS客户端未成功更改用户的权限，则RADIUS客户端回应动态授权请求拒绝报文给RADIUS服务器。
DM-Request	用户离线请求报文。当管理员需要让某个在线的用户下线时，可以通过RADIUS服务器发送一个用户离线请求报文给RADIUS客户端，使RADIUS客户端终结用户的连接。
DM-ACK	用户离线请求接受报文。如果RADIUS客户端已经切断了用户的连接，则RADIUS客户端回应用户离线请求接受报文给RADIUS服务器。
DM-NAK	用户离线请求拒绝报文。如果RADIUS客户端无法切断用户的连接，则RADIUS客户端回应用户离线请求拒绝报文给RADIUS服务器。

交互流程

CoA（Change of Authorization）是指用户认证成功后，管理员可以通过RADIUS协议来修改在线用户的权限或对其进行重认证。CoA的报文交互流程如图1-13所示。

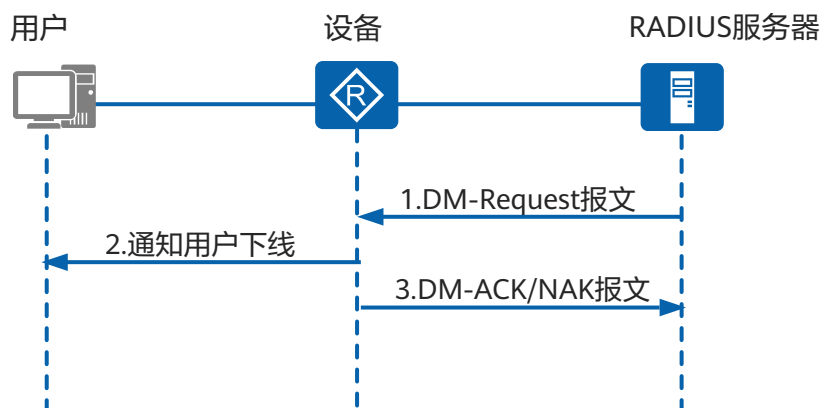
图 1-13 CoA 的报文交互流程



1. RADIUS服务器根据业务信息，向设备发送CoA-Request报文，请求更改用户的授权信息。该报文中可以包括ACL规则等授权。
2. 设备收到CoA-Request报文后，与设备上的用户信息匹配来识别用户。如果匹配成功，则更改用户的授权信息；如果匹配失败，则保持用户原有授权信息。
3. 设备回应CoA-ACK/NAK报文。
 - 如果更改成功，则设备向RADIUS服务器回应CoA-ACK报文。
 - 如果更改失败，则设备向RADIUS服务器回应CoA-NAK报文。
4. 如果用户不存在，则不回应。

DM（Disconnect Message）是指用户下线报文，即由RADIUS服务器主动发起的强制用户下线的报文。DM的报文交互流程如图1-14所示。

图 1-14 DM 的报文交互流程



1. 管理员在RADIUS服务器上强制用户下线，RADIUS服务器向设备发送DM-Request报文，请求用户下线。
2. 设备收到DM-Request报文后，与设备上的用户信息匹配来识别用户。如果匹配成功，则通知用户下线；如果匹配失败，则用户保持在线。
3. 设备回应DM-ACK/NAK报文。
 - 如果用户成功下线，设备给RADIUS服务器回应DM-ACK报文。
 - 如果用户未下线，设备给RADIUS服务器回应DM-NAK报文。
4. 如果用户不存在，则不回应。

与用户上线授权或用户主动下线过程相比，CoA/DM的特点是请求报文是由服务器发送的，回应报文是由设备发送的，成功则回应ACK报文、失败则回应NAK报文。

会话识别

NAS设备为用户提供的每一个服务构成一个会话，会话的开头定义为首次提供服务的点，会话的结束定义为服务结束点。

设备接收到RADIUS服务器的CoA-Request报文或者DM-Request报文后，根据报文中的某些RADIUS属性来识别用户。用来识别用户的RADIUS属性包括：

- RADIUS标准属性：User-Name（1）
- RADIUS标准属性：Acct-Session-ID（44）
- RADIUS标准属性：Framed-IP-Address（8）
- RADIUS标准属性：Calling-Station-Id（31）

匹配的方式包括以下两种：

- **any方式**
其中一个属性与设备上的用户信息进行匹配检查。识别用户所用的RADIUS属性优先级为：Acct-Session-ID（44）> Calling-Station-Id（31）> Framed-IP-Address（8）。按照优先级在请求报文中查找属性，优先找到哪个属性就用哪个属性与设备上的用户信息进行匹配，匹配成功时，设备回应ACK报文，否则回应NAK报文。
- **all方式**
所有的属性与设备上的用户信息进行匹配检查。识别用户所用的RADIUS属性包括：Acct-Session-ID（44）、Calling-Station-Id（31）、Framed-IP-Address（8）和User-Name（1）。请求报文中以上属性都要与设备上的用户信息进行匹配，全部匹配成功时，设备回应ACK报文，否则回应NAK报文。

错误码说明

RADIUS服务器的CoA-Request报文或DM-Request报文与设备上的用户信息匹配失败时，设备会在回应的CoA-NAK报文或DM-NAK报文中通过错误码描述失败的原因。错误码介绍请参见[表1-8](#)和[表1-9](#)。

表 1-8 CoA-NAK 报文中的错误码

名称	数值	说明
RD_DM_ERRCODE_MISSING_ATTRIBUTE	402	请求报文中缺少关键属性，导致RADIUS属性完整性检查失败
RD_DM_ERRCODE_INVALID_REQUEST	404	对请求报文进行属性解析时，解析失败
RD_DM_ERRCODE_INVALID_ATTRIBUTE_VALUE	407	请求报文中包含不支持或不存在的属性，导致属性检查失败。 授权检查的内容包括：VLAN、ACL、CAR、重定向ACL编号以及基于接口的认证用户不支持授权华为RADIUS扩展属性RD_hw_URL_Flag和RD_hw_Portal_URL 可能出现的错误包括： • 授权的业务方案不存在 • 授权的QoS模板不存在或QoS模板中未配置用户队列 • 授权的上下行优先级超过最大值 • 授权的UCL组索引值不在规格范围内 • 解析ISP VLAN和出端口信息错误 • 重认证属性与其他属性同时授权
RD_DM_ERRCODE_SESSION_CONTEXT_NOT_FOUND	503	会话请求失败。包括： • 当前针对请求用户的授权正在处理 • 申请RADIUS临时表失败 • 用户信息不匹配或未找到用户 • 用户非RADIUS认证用户
RD_DM_ERRCODE_RESOURCES_UNAVAILABLE	506	其他授权失败的情况使用该错误码

表 1-9 DM-NAK 报文中的错误码

名称	数值	说明
RD_DM_ERRCODE_INVALID_REQUEST	404	对请求报文进行属性解析时，解析失败
RD_DM_ERRCODE_SESSION_CONTEXT_NOT_REMOVABLE	504	用户删除失败。

1.2.4.8 RADIUS 属性

- RADIUS属性即RADIUS报文中的Attribute字段，用来携带专门的认证、授权和计费信息。本节介绍的内容包括：
- [RADIUS标准属性](#)
 - [华为RADIUS扩展属性](#)
 - [华为支持的其他厂商RADIUS扩展属性](#)
 - [RADIUS报文对于RADIUS属性的支持情况](#)
 - [注意事项](#)

RADIUS 标准属性

协议RFC2865、RFC2866和RFC3576标准规定了RADIUS标准属性，所有主流设备厂商基本上都支持。具体请参见[表1-10](#)。

表 1-10 RADIUS 标准属性

属性编号	属性名	属性类型	属性说明
1	User-Name	string	需要进行认证的用户名。可以采用带域名的“用户名@域名”格式，也可以采用不带域名的“用户名”格式。 说明 本属性无法通过radius-attribute set attribute-name attribute-value命令下发携带中文的值。
2	User-Password	string	需要进行认证的用户密码，仅对PAP（ Password Authentication Protocol ）认证有效。
3	CHAP-Password	string	需要进行认证的用户密码，仅对CHAP（ Challenge Handshake Authentication Protocol ）认证有效。
4	NAS-IP-Address	ip address	认证请求报文中携带的NAS的IP（ Internet Protocol ）地址。缺省情况下，属性值为NAS发送认证请求报文的源IP地址。可以通过命令radius-attribute nas-ip { ip-address ap-info }修改属性值为NAS上指定的IP地址或者AP的IP地址。
5	NAS-Port	integer	用户接入的物理端口号，可根据实际需要转换成不同格式： • “new”模式：槽位号（ 8位 ）+子槽位号（ 4位 ）+端口号（ 8位 ）+VLAN（ Virtual Local Area Network ）ID（ 12位 ）。 • “old”模式：槽位号（ 12位 ）+端口号（ 8位 ）+VLAN ID（ 12位 ）。 • ADSL接入用户的物理端口形式特殊：槽位号（ 4位 ）+子槽位号（ 2位 ）+端口号（ 2位 ）+VPI（ 8位 ）+VCI（ 16位 ）。

属性编号	属性名	属性类型	属性说明
6	Service-Type	integer	用户申请认证的业务类型： 2（Framed）：PPP、802.1X、静态用户和MAC认证用户（用户名使用固定格式）等接入用户。 6（Administrative）：管理员用户。 8（Authenticate Only）：只重认证不重授权。 10（Call Check）：MAC认证用户（用户名使用MAC地址格式）和MAC旁路认证用户。
7	Framed-Protocol	integer	用户Frame类型业务的封装协议： - 对于非管理员用户，Framed-Protocol的值固定为1。 - 对于管理员用户，Framed-Protocol的值固定为6。
8	Framed-IP-Address	ipaddress	用户的IP地址。
9	Framed-IP-Netmask	ipaddress	用户的地址掩码，该属性必须和 Framed-IP-Address 一起使用。
12	Framed-MTU	integer	NAS与服务器之间数据链路的MTU值。例如在802.1X的EAP（Extensible Authentication Protocol）方式认证中，NAS通过Framed-MTU值指示Server发送EAP报文的最大长度，防止EAP报文大于数据链路MTU导致的报文丢失。 说明 只有EAP中继认证方式会携带该属性值。
14	Login-IP-Host	ipaddress	管理员用户的IP地址： - 如果该属性取值为0或0xFFFFFFFF，表示不对管理员用户的IP地址进行检查。 - 如果该属性取值为其他值，表示需要检查管理员用户的IP地址和通过这个属性下发的地址是否一致。
15	Login-Service	integer	管理员用户可以使用的服务类型： 0：Telnet。 5：X25-PAD。 50：SSH。 51：FTP。 52：Terminal。 说明 一个属性中可以包含多个服务类型。

属性编号	属性名	属性类型	属性说明
18	Reply-Message	string	认证成功或拒绝消息： - 当该属性用于认证接受报文时，表示成功消息。 - 当该属性用于认证拒绝报文时，表示拒绝消息。
19	Callback-Number	string	认证服务器回应的可以显示给用户的信息，例如移动电话号码等。
22	Framed-Route	string	表示由RADIUS服务器为设备上的用户提供路由信息，格式为：Destination/Mask（目的网段/子网掩码）NextHop（下一跳）Metric（度量值），例如192.168.1.0/24 192.168.1.1 1。 如果NextHop取值为0.0.0.0，则表示使用用户的IP地址作为下一跳地址。设备只支持获取一个Metric取值，如果RADIUS服务器下发属性时携带有多个Metric，则设备只获取第一个Metric的值。 说明 目前此属性不支持为设备上的PPPoE用户提供路由信息。
24	State	string	如果RADIUS服务器发送给设备的认证挑战报文中包含该属性值，则设备在后续的认证请求报文中必须包含相同的值。 该属性由服务器在Access-Accept中发送到客户端，Access-Accept还包括值为RADIUS-Request的终止操作属性。如果NAS在当前会话终止时通过发送新的Access-Request来执行终止操作，则它必须在该Access-Request中包含未更改的State属性。
25	Class	string	如果RADIUS服务器发送给NAS设备的认证接受报文中包含该属性值，则NAS在后续发送的所有计费请求报文中必须包含相同的值。
26	Vendor-Specific	string	厂商自定义属性，具体请参见表1-11。一个报文中可以有一个或多个私有属性，每个私有属性中可以有一个或多个子属性。

属性编号	属性名	属性类型	属性说明
27	Session-Timeout	integer	在认证接受报文中，该属性表示为用户提供服务的剩余时间，单位为秒。 在认证挑战报文中，该属性表示EAP认证用户的重认证时长。 该属性的取值为0时： ● 如果未配置命令aaa-author session-timeout invalid-value enable，服务器下发的Session-Timeout属性不生效，用户的下线或者重认证周期由设备的配置决定。 ● 如果配置了命令aaa-author session-timeout invalid-value enable，服务器下发的Session-Timeout属性生效，设备不会对用户进行下线或重认证。 说明 该属性只对802.1X认证、MAC认证、Portal认证和PPPoE认证用户生效。 RADIUS服务器只下发该属性时，29号属性Termination-Action的默认值设置为0（强制用户下线）。
28	Idle-Timeout	integer	会话结束之前，允许用户持续空闲的最大时间，即用户的闲置切断时间，以秒为单位。 说明 ● 该属性对管理员用户、PPPoE用户和Portal用户生效。 ● 该属性可以与命令idle-cut（业务方案视图）配置的流量和方向配合使用。当没有授权业务方案或者业务方案没有配置该命令时，用户在闲置切断时间内无上行流量时，切断用户。 ● 当对接V200R009C00之前版本的AP设备时，闲置切断时间向上取整分钟，例如60s取1分钟、61-119s取2分钟。
29	Termination-Action	integer	用户的业务终止方式： ● 0：强制用户下线。 ● 1：重认证。 说明 该属性只对802.1X认证和MAC认证用户生效。认证点配置在VLANIF接口上的MAC认证用户不支持授权Termination-Action=1。 RADIUS服务器只下发该属性时，27号属性Session-Timeout的默认值设置为3600s（802.1X认证用户）或1800s（MAC认证用户）。

属性编号	属性名	属性类型	属性说明
30	Called-Station-Id	string	NAS设备的号码信息。 - 对于有线用户，该属性一般情况下为NAS设备的MAC地址。 - 对于无线用户，该属性表示AP的MAC地址和SSID。 说明 本属性无法通过radius-attribute set attribute-name attribute-value命令下发携带中文的值。
31	Calling-Station-Id	string	客户端的号码信息，一般为用户的MAC地址。 说明 本属性无法通过radius-attribute set attribute-name attribute-value命令下发携带中文的值。
32	NAS-Identifier	string	NAS设备标识。缺省情况下，属性值为NAS设备的主机名。可以通过命令radius-server nas-identifier-format { hostname vlan-id ap-info }修改属性值为用户的VLAN ID或AP的MAC地址。 说明 本属性无法通过radius-attribute set attribute-name attribute-value命令下发携带中文的值。
40	Acct-Status-Type	integer	计费请求报文Accounting-Request的类型： 1：开始计费报文。 2：停止计费报文。 3：实时计费报文。
41	Acct-Delay-Time	integer	用于上报发送该计费报文花费的时间，单位为秒(不包括网络传输时间)。
44	Acct-Session-Id	string	计费ID，同一个连接的开始计费、实时计费和停止计费报文的连接的计费ID必须相同。 计费ID格式为：7位主机名 + 2位槽号 + 1位子卡号 + 2位端口号 + 4位外层VLAN + 5位内层VLAN + 6位CPU（Central Processing Unit）Tick + 2位用户ID的前缀+5位用户ID。
45	Acct-Authentic	integer	用户的认证模式： 1：RADIUS认证。 2：本地认证。 3：其他远端认证。
46	Acct-Session-Time	integer	用户的在线时长，以秒为单位。 说明 当用户上线后，如果管理员对设备的系统时间进行了更改，设备计算出的用户在线时长可能存在误差。

属性编号	属性名	属性类型	属性说明
49	Acct-Terminate-Cause	integer	用户连接中断的原因： • User-Request(1)：用户主动请求下线。 • Lost Carrier(2)：握手失败或心跳超时，例如ARP探测失败、PPP握手失败等。 • Lost Service(3)：对端设备发起的连接拆除。 • Idle Timeout(4)：闲置切断。 • Session Timeout(5)：时间限制切断或流量限制切断。 • Admin Reset(6)：管理员指令性切断。 • Admin Reboot(7)：管理员重启设备。 • Port Error(8)：端口故障。 • NAS Error(9)：设备发生内部错误。 • NAS Request(10)：设备由于资源变化请求下线。 • NAS Reboot(11)：设备自动重启。 • Port Unneeded(12)：端口不可用。 • Port Preempted(13)：端口被抢占。 • Port Suspended(14)：端口挂起。 • Service Unavailable(15)：业务不可用。 • Callback(16)：NAS结束了当前的会话以进行回呼。 • User Error(17)：用户故障，如用户认证失败或超时等。 • Host Request(18)：主机请求。
50	Acct-Multi-Session-Id	string	计费ID，应用于多链路会话场景。
60	CHAP-Challenge	string	CHAP认证的质询字段，该质询字段是CHAP认证中由NAS生成的用于MD5（Message Digest algorithm 5）计算的随机序列。
61	NAS-Port-Type	integer	NAS的端口类型。 • 有线用户默认类型是Ethernet（15）。 • 无线用户默认类型是Wireless - IEEE 802.11（19）。
64	Tunnel-Type	integer	隧道采用的协议类型，目前仅支持取值为13，表示VLAN协议。
65	Tunnel-Medium-Type	integer	隧道承载媒介类型，固定为6，表示以太类型。

属性编号	属性名	属性类型	属性说明
66	Tunnel-Client-Endpoint	string	隧道客户端地址。
67	Tunnel-Server-Endpoint	string	隧道服务端地址。
75	Password-Retry	integer	密码重试次数。
79	EAP-Message	string	用于封装EAP报文，实现RADIUS协议对EAP认证方式的支持。EAP报文长度超过253时支持封装成多个属性，一个RADIUS报文可携带多个该字段。
80	Message-Authenticator	string	用于对认证报文进行认证和校验，防止非法报文欺骗。该属性仅在RADIUS协议支持EAP认证方式时使用。
81	Tunnel-Private-Group-ID	string	隧道私有组标识，目前通过该属性下发用户VLAN。
82	Tunnel-Assignment-Id	string	隧道中被分配的特定ID。
83	Tunnel-Preference	string	隧道优先级。
85	Acct-Interim-Interval	integer	用户的实时计费间隔，以秒为单位，建议该值不要小于600秒。支持下发范围60～3932100。

属性编号	属性名	属性类型	属性说明
87	NAS-Port-Id	string	用户接入的端口号，包括以下格式： - new: 对于以太网接入用户，NAS端口ID形式为：“slot = XX; subslot = XX; port = XXX; vlanid = XXXX”，其中，slot取值范围是0~15或64，subslot取值范围是0~15，port取值范围是0~255，vlanid取值范围是1~4094。 - 对于ADSL接入用户：NAS端口ID形式为“slot = XX; subslot = X; port = X; vpi = XXX; vci = XXXXX”，其中，slot取值范围是0~15，subslot取值范围是0~9，port取值范围是0~9，vpi取值范围是0~255，vci取值范围是0~65535。 - 对于ADSL接入用户：NAS端口ID形式为“slot = XX; subslot = X; port = X; VPI = XXX; VCI = XXXXX”，其中，slot取值范围是0~15，Subslot取值范围是0~9，Port取值范围是0~9，VPI取值范围是0~255，VCI取值范围是0~65535。 - old: 对于以太网接入用户，NAS端口ID形式为：端口号（两个字符）+子槽号（两个字节）+卡号（三个字节）+VLANID（9个字符）。 - 对于ADSL接入用户，NAS端口ID形式为：端口号（两个字符）+子槽号（两个字节）+卡号（三个字节）+VPI（8个字符）+VCI（16个字符），字节数不够的，在前面补零。 - 对于ADSL接入用户，NAS端口ID形式为：端口号（两个字符）+子槽号（两个字节）+卡号（三个字节）+VPI（8个字符）+VCI（16个字符），字节数不够的，在前面补零。 说明 本属性无法通过radius-attribute set attribute-name attribute-value命令下发携带中文的值。
88	Framed-Pool	string	地址池信息，该属性只在认证成功报文中携带，作为授权信息。
89	Chargeable-User-Identity	string	由服务器下发的计费标识。支持情况由命令 radius-server support chargeable-user-identity [not-reject] 配置。
90	Tunnel-Client-Auth-Id	string	隧道建立过程中认证阶段使用的客户端隧道ID。
91	Tunnel-Server-Auth-Id	string	隧道建立过程中认证阶段使用的服务端隧道ID。

属性编号	属性名	属性类型	属性说明
95	NAS-IPv6-Address	ipaddr	NAS设备发送的认证请求报文中携带的设备IPv6地址。NAS-IPv6-Address可以和NAS-IP-Address同时出现在报文中。
98	Login-IPv6-Host	ipaddr	IPv6管理员用户RADIUS认证携带用户的IPv6地址。
101	Error-Cause	integer	授权失败的原因。 201 Residual Session Context Removed：残留会话上下文已删除。 202 Invalid EAP Packet (Ignored)：无效的EAP数据包（忽略）。 401 Unsupported Attribute：不支持的属性。 402 Missing Attribute：缺少属性。 403 NAS Identification Mismatch：NAS标识不匹配。 404 Invalid Request：无效请求。 405 Unsupported Service：不支持的服务类型。 406 Unsupported Extension：不支持的扩展。 501 Administratively Prohibited：管理禁止。 502 Request Not Routable (Proxy)：请求不可路由（代理）。 503 Session Context Not Found：找不到会话上下文。 504 Session Context Not Removable：会话上下文不可删除。 505 Other Proxy Processing Error：其他代理处理错误。 506 Resources Unavailable：资源不可用。 507 Request Initiated：请求已启动。
121	Input-Peak-Rate	integer	上行峰值速率。
122	Input-Average-Rate	integer	上行平均速率。
123	Input-Basic-Rate	integer	上行基本速率。
124	Output-Peak-Rate	integer	下行峰值速率。

属性编号	属性名	属性类型	属性说明
125	Output-Average-Rate	integer	下行平均速率。
126	Output-Basic-Rate	integer	下行基本速率。
135	Ascend-Client-Primary-Dns	ipaddress	DNS服务器地址1。
136	Ascend-Client-Secondary-Dns	ipaddress	DNS服务器地址2。
192	Remote-IP-Host	ipaddress	远程IP主机。
195	HW-SecurityStr	string	EAP透传认证时用于携带用户的安全信息。

华为 RADIUS 扩展属性

RADIUS协议具有良好的可扩展性，协议（RFC2865）中定义的26号属性（Vendor-Specific）用于设备厂商对RADIUS进行扩展，以实现标准RADIUS没有定义的功能。华为公司的RADIUS扩展属性请参见表1-11。

说明

RADIUS扩展属性中包含各个设备厂商的厂商代号Vendor-ID，华为公司的Vendor-ID是2011。

表 1-11 华为 RADIUS 扩展属性

属性编号	属性名	属性类型	属性说明
26-1	HW-Input-Peak-Information-Rate	integer	用户接入到NAS的峰值速率，以bit/s为单位。整型，4字节。
26-2	HW-Input-Committed-Information-Rate	integer	用户接入到NAS的平均速率，以bit/s为单位。整型，4字节。

属性编号	属性名	属性类型	属性说明
26-3	HW-Input-Committed-Burst-Size	integer	用户接入到NAS的承诺突发尺寸，以bit/s为单位。整型，4字节。
26-4	HW-Output-Peak-Information-Rate	integer	从NAS到用户的峰值速率，以bit/s为单位。整型，4字节。
26-5	HW-Output-Committed-Information-Rate	integer	从NAS到用户的平均速率，以bit/s为单位。整型，4字节。
26-6	HW-Output-Committed-Burst-Size	integer	从NAS到用户的承诺突发尺寸，以bit/s为单位。整型，4字节。
26-15	HW-Remanent-Volume	integer	剩余流量。单位为KB。
26-26	HW-Connect-ID	integer	用户连接的索引。
26-28	HW-FTP-Directory	string	FTP用户的初始目录。
26-29	HW-Exec-Privilege	integer	管理用户（例如Telnet用户）的用户级别，有效值范围0～15。授权大于等于16的为无效值。
26-31	HW-Qos-Data	string	QoS模板名，最大长度为31字节。RADIUS服务器通过该字段下发QoS模板，QoS模板必须在设备上已存在。
26-59	HW-NAS-Startup-Time-Stamp	integer	NAS设备启动时间，从1970年1月1日0点0分0秒时开始计算（以秒为单位）。
26-60	HW-IP-Host-Address	string	认证和计费报文中携带的用户IP地址和MAC地址，格式为“A.B.C.D hh:hh:hh:hh:hh:hh”，IP地址和MAC地址之间必须用空格分开。 如果在认证时用户的IP地址尚未有效，则A.B.C.D设置为255.255.255.255。
26-75	HW-Primary-WINS	ipaddr	用户认证成功后，RADIUS下发的主WINS服务器地址。
26-76	HW-Second-WINS	ipaddr	用户认证成功后，RADIUS下发的备WINS服务器地址。

属性编号	属性名	属性类型	属性说明
26-77	HW-Input-Peak-Burst-Size	integer	上行峰值尺寸，以bit/s为单位。
26-78	HW-Output-Peak-Burst-Size	integer	下行峰值尺寸，以bit/s为单位。
26-82	HW-Data-Filter	string	RADIUS服务器通过该属性将下发给用户。 以下为服务器上填写的属性值举例： \$1 permit dst 10.0.239.192/26 \$2 permit udp src any 8080 \$3 permit icmp echo dst 10.1.1.1/24 \$5 deny
26-94	HW-VPN-Instance	string	用户认证成功后，RADIUS下发的VPN实例名，指定用户属于哪个VPN。 RADIUS下发该属性时，需要同时下发RADIUS标准属性8（Framed-IP-Address）。
26-135	HW-Client-Primary-DNS	ipaddress	用户认证成功后，RADIUS下发的主DNS服务器地址。
26-136	HW-Client-Secondary-DNS	ipaddress	用户认证成功后，RADIUS下发的备DNS服务器地址。
26-138	HW-Domain-Name	string	用户实际所属域的域名。不一定是用户名中的域名，可能是强制域的域名。
26-141	HW-AP-Information	string	无线用户认证时携带的AP的MAC地址。
26-142	HW-User-Information	string	RADIUS服务器为EAPoL（Extensible Authentication Protocol over LAN）用户下发的用户安全检查控制信息，通知用户需要进行哪些安全检查。
26-146	HW-User-Policy	string	业务方案的名称。业务方案下通常配置用户的授权信息和策略。

属性编号	属性名	属性类型	属性说明
26-153	HW-Access-Type	integer	设备发送给RADIUS服务器的认证请求和计费请求报文中携带的用户接入类型。包括： • 1: Dot1x用户。 • 2: MAC认证用户和MAC旁路认证用户。 • 3: Portal认证用户。 • 4: 静态用户。 • 6: 管理用户。 • 7: PPP用户。 • 8: Portal Mac-first
26-155	HW-URL-Flag	integer	是否需要用户强推URL，比如和属性HW-Portal-URL结合使用。其中： • 0: 不需要。 • 1: 需要。
26-156	HW-Portal-URL	string	用户强推URL（Uniform Resource Locator）。如果RADIUS服务器下发的信息匹配了设备配置的URL模板，则使用URL模板下配置的URL，否则，按RADIUS服务器下发的字符串进行推送。

属性编号	属性名	属性类型	属性说明
26-201	HW-User-Extend-Info	string	用户扩展信息。认证请求报文和计费请求报文中携带该信息，可携带多个。目前定义如下： • User-Position：上网服务场所编码。 • User-Position-Type：上网服务场所类型。 • AP-Device-Code：AP设备编号。 • AP-POS-X：移动AP经度。 • AP-POS-Y：移动AP纬度。 • Wifi-Density：场强信息。 • HW-Access-Time：用户接入时间，以秒为单位，表示从1970年1月1日零点零分零秒以来的绝对秒数。802.1X认证用户仅支持该信息。 • wan-src-ip：源外网IPv4/IPv6地址。 IPv4地址采用无符号整型主机序表示，如：2880036141；IPv6地址字段格式采用冒号分十六进制表示法，格式为XXXX:XXXX:XXXX:XXXX:XXXX:XXXX:XXXX:XXXX，如CDCD:910A:2222:5498:1111:3900:2020:6328。 • wan-src-start-port：源外网IPv4/IPv6起始端口号。 其端口号为TCP/IP协议端口，取值范围为0～65535。若仅有唯一端口，起始端口号和结束端口号相同。 • wan-src-end-port：源外网IPv4/IPv6结束端口号。 其端口号为TCP/IP协议端口，取值范围为0～65535。 仅MAC认证和Portal认证支持该属性。
26-237	HW-Web-Authen-Info	string	Portal服务器发给RADIUS服务器的信息，设备直接透传该信息给RADIUS服务器。比如用户选择的下次登录免认证选项和时间信息，RADIUS服务器根据此信息将用户MAC保存一定的时间，下次用户登录时优选MAC认证，无需再次弹出登录页面。后续可用于EAP等复杂方式的透传认证。
26-241	HW-User-Addr-Network	ipaddress	用户地址网段。
26-242	HW-DNS-Domain-Name	string	DNS域名。

属性编号	属性名	属性类型	属性说明
26-243	HW-Auto-Update-URL	string	版本升级路径URL地址。
26-244	HW-Reachable-Detect	string	服务器可达性探测信息，认证报文可携带该属性，表示该报文为服务器探测报文。
26-247	HW-Tariff-Input-Octets	string	设备通过计费报文向服务器发送的指定费率级别流量的上行字节数，单位可以为Byte，KByte，MByte或GByte，格式为“费率级别: 上行字节数; ”。
26-248	HW-Tariff-Output-Octets	string	设备通过计费报文向服务器发送的指定费率级别流量的下行字节数，单位可以为Byte，KByte，MByte或GByte，格式为“费率级别: 下行字节数; ”。
26-249	HW-Tariff-Input-Gigawords	string	指定费率级别流量的上行字节数是4G的多少倍，与 HW-Tariff-Input-Octets 属性共同决定指定费率级别流量的上行字节数。
26-250	HW-Tariff-Output-Gigawords	string	指定费率级别流量的下行字节数是4G的多少倍，与 HW-Tariff-Output-Octets 属性共同决定指定费率级别流量的下行字节数。
26-254	HW-Version	string	设备的软件版本号。 说明 本属性无法通过 radius-attribute set attribute-name attribute-value 命令下发携带中文的值。
26-255	HW-Product-ID	string	NAS的产品名称。

华为支持的其他厂商 RADIUS 扩展属性

表 1-12 华为支持的其他厂商 RADIUS 扩展属性

属性编号	属性名	属性类型	属性说明
MICROS OFT-16	MS-MPPE-Send-Key	string	MPPE发送密钥。
MICROS OFT-17	MS-MPPE-Recv-Key	string	MPPE接收密钥。

RADIUS 属性在报文中的支持情况

不同的RADIUS报文对于RADIUS属性的支持情况也不相同。RADIUS属性在报文中的支持情况包括：

- RADIUS认证报文中属性的支持情况，如表1-13所示。
- RADIUS计费报文中属性的支持情况，如表1-14所示。
- RADIUS授权报文中属性的支持情况，如表1-15所示。

说明

- 1：表示该属性在该类型报文中一定出现一次；
- 0：表示该属性在该类型报文中一定不能出现（即使出现也不起任何作用，该属性将被丢弃）；
- 0-1：表示该属性在该类型报文中可能出现一次，也可能不出现；
- 0+：表示零个或多个该属性可能出现在该类型报文中。

如下表格中只体现设备支持的属性，即RADIUS属性在报文中的支持情况全部为0的不体现。

表 1-13 RADIUS 认证报文中属性的支持情况

属性	Access-Request	Access-Accept	Access-Reject	Access-Challenge
User-Name(1)	0-1	0-1	0	0
User-Password(2)	0-1	0	0	0
CHAP-Password(3)	0-1	0	0	0
NAS-IP-Address(4)	0-1	0	0	0
NAS-Port(5)	0-1	0	0	0
Service-Type(6)	0-1	0-1	0	0
Framed-Protocol(7)	0-1	0-1	0	0
Framed-IP-Address(8)	0-1	0-1	0	0
Framed-IP-Netmask(9)	0-1	0-1	0	0
Filter-Id(11)	0	0+	0	0
Framed-MTU(12)	0-1	0-1	0	0
Login-IP-Host(14)	0+	0+	0	0
Login-Service(15)	0	0-1	0	0
Reply-Message(18)	0	0+	0+	0+
Callback-Number(19)	0-1	0-1	0	0
Framed-Route(22)	0	0+	0	0
State(24)	0-1	0-1	0	0-1
Class(25)	0	0+	0	0

属性	Access-Request	Access-Accept	Access-Reject	Access-Challenge
Vendor-Specific(26)	0+	0+	0	0+
Session-Timeout(27)	0	0-1	0	0-1
Idle-Timeout(28)	0	0-1	0	0-1
Termination-Action(29)	0	0-1	0	0
Called-Station-Id(30)	0-1	0	0	0
Calling-Station-Id(31)	0-1	0	0	0
NAS-Identifier(32)	0-1	0	0	0
Login-LAT-Service(34)	0-1	0-1	0	0
Login-LAT-Node(35)	0-1	0-1	0	0
Login-LAT-Group(36)	0-1	0-1	0	0
Framed-AppleTalk-Link(37)	0	0-1	0	0
Framed-AppleTalk-Network(38)	0	0+	0	0
Framed-AppleTalk-Zone(39)	0	0-1	0	0
Acct-Session-id(44)	1	0	0	0
CHAP-Challenge(60)	0-1	0	0	0
NAS-Port-Type(61)	0-1	0	0	0
Login-LAT-Port(63)	0-1	0-1	0	0
Tunnel-Type(64)	0	0-1	0	0
Tunnel-Medium-Type(65)	0	0-1	0	0
Tunnel-Client-Endpoint(66)	0-1	0-1	0	0
Tunnel-Server-Endpoint(67)	0-1	0-1	0	0
Password-Retry(75)	0	0-1	0	0
EAP-Message(79)	0-1	0-1	0-1	0-1
Message-Authenticator(80)	0-1	0-1	0-1	0-1
Tunnel-Private-Group-ID(81)	0	0-1	0-1	0

属性	Access-Request	Access-Accept	Access-Reject	Access-Challenge
Tunnel-Assignment-Id(82)	0	0-1	0	0
Tunnel-Preference(83)	0	0-1	0	0
Acct-Interim-Interval(85)	0	0-1	0	0
NAS-Port-Id(87)	0-1	0	0	0
Framed-Pool(88)	0	0-1	0	0
Chargeable-User-Identity(89)	0-1	0-1	0	0
Tunnel-Client-Auth-Id(90)	0	0+	0	0
Tunnel-Server-Auth-Id(91)	0	0+	0	0
NAS-IPv6-Address(95)	0-1	0	0	0
Login-IPv6-Host(98)	0-1	0	0	0
Input-Peak-Rate(121)	0	0-1	0	0
Input-Average-Rate(122)	0	0-1	0	0
Input-Basic-Rate(123)	0	0-1	0	0
Output-Peak-Rate(124)	0	0-1	0	0
Output-Average-Rate(125)	0	0-1	0	0
Output-Basic-Rate(126)	0	0-1	0	0
Ascend-Client-Primary-Dns(135)	0	0-1	0	0
Ascend-Client-Secondary-Dns(136)	0	0-1	0	0
Remote-IP-Host(192)	0-1	0	0	0
HW-SecurityStr(195)	0-1	0	0	0
HW-Input-Peak-Information-Rate(26-1)	0	0-1	0	0
HW-Input-Committed-Information-Rate(26-2)	0	0-1	0	0
HW-Input-Committed-Burst-Size(26-3)	0	0-1	0	0
HW-Output-Peak-Information-Rate(26-4)	0	0-1	0	0

属性	Access-Request	Access-Accept	Access-Reject	Access-Challenge
HW-Output-Committed-Information-Rate(26-5)	0	0-1	0	0
HW-Output-Committed-Burst-Size(26-6)	0	0-1	0	0
HW-Remanent-Volume(26-15)	0	0-1	0	0
HW-Connect-ID(26-26)	1	0	0	0
Ftp-directory(26-28)	0	0-1	0	0
HW-Exec-Privilege(26-29)	0	0-1	0	0
HW-Qos-Data(26-31)	0	0-1	0	0
HW-NAS-Startup-Time-Stamp(26-59)	1	0	0	0
HW-IP-Host-Address(26-60)	1	0	0	0
HW-Primary-WINS(26-75)	0	0-1	0	0
HW-Second-WINS(26-76)	0	0-1	0	0
HW-Input-Peak-Burst-Size(26-77)	0	0-1	0	0
HW-Output-Peak-Burst-Size(26-78)	0	0-1	0	0
HW-VPN-Instance(26-94)	0	0-1	0	0
HW-Client-Primary-DNS(26-135)	0	0-1	0	0
HW-Client-Secondary-DNS(26-136)	0	0-1	0	0
HW-Domain-Name(26-138)	0-1	0	0	0
HW-AP-Information(26-141)	0-1	0	0	0
HW-User-Information(26-142)	0	0-1	0	0
HW-Web-Proxy-Name(26-143)	0	0-1	0	0
HW-Port-Forward-Name(26-144)	0	0-1	0	0

属性	Access-Request	Access-Accept	Access-Reject	Access-Challenge
HW-IP-Forwarding-Name(26-145)	0	0-1	0	0
HW-User-Policy(26-146)	0	0-1	0	0
HW-Access-Type(26-153)	1	0-1	0	0
HW-IPv6-Redirect-ACL(26-178)	0	0-1	0	0
HW-User-Extend-Info(26-201)	0-1	0	0	0
HW-Web-Authen-Info(26-237)	0-1	0	0	0
HW-User-Addr-Network(26-241)	0	0-1	0	0
HW-DNS-Domain-Name(26-242)	0	0-1	0	0
HW-Auto-Update-URL(26-243)	0	0-1	0	0
HW-Reachable-Detect(26-244)	0-1	0	0	0
HW-Version(26-254)	1	0	0	0
HW-Product-ID(26-255)	1	0	0	0
MS-MPPE-Send-Key(MICROSOFT-16)	0	0-1	0	0
MS-MPPE-Recv-Key(MICROSOFT-17)	0	0-1	0	0

表 1-14 RADIUS 计费报文中属性的支持情况

属性	Accounting-Request (Start)	Accounting-Request (Interim-Update)	Accounting-Request (Stop)	Accounting-Response (start)	Accounting-Response (Interim-Update)	Accounting-Response (Stop)
User-Name(1)	0-1	0-1	0-1	0	0	0
NAS-IP-Address(4)	0-1	0-1	0-1	0	0	0

属性	Accounting-Request (Start)	Accounting-Request (Interim-Update)	Accounting-Request (Stop)	Accounting-Response (start)	Accounting-Response (Interim-Update)	Accounting-Response (Stop)
NAS-Port(5)	0-1	0-1	0-1	0	0	0
Service-Type(6)	0-1	0-1	0-1	0	0	0
Framed-Protocol(7)	0-1	0-1	0-1	0	0	0
Framed-IP-Address(8)	0-1	0-1	0-1	0-1	0-1	0-1
Class(25)	0+	0+	0+	0	0	0
Vendor-Specific(26)	0+	0+	0+	0	0	0
Session-Timeout(27)	0-1	0-1	0-1	0-1	0-1	0
Called-Station-Id(30) 说明 对于PPP接入认证用户，该属性非必带属性。如果认证请求报文中没有携带该属性，计费请求报文中也不会携带该属性。	0-1	0-1	0-1	0	0	0
Calling-Station-Id(31)	0-1	0-1	0-1	0	0	0
NAS-Identifier(32)	0-1	0-1	0-1	0	0	0
Acct-Status-Type(40)	1	1	1	0	0	0
Acct-Delay-Time(41)	0-1	0-1	0-1	0	0	0
Acct-Output-Octets(43)	0-1	0-1	0-1	0	0	0
Acct-Session-Id(44)	1	1	1	0	0	0
Acct-Authentic(45)	0-1	0-1	0-1	0	0	0
Acct-Session-Time(46)	0-1	0-1	0-1	0	0	0
Acct-Terminate-Cause(49)	0	0	1	0	0	0

属性	Accounting-Request (Start)	Accounting-Request (Interim-Update)	Accounting-Request (Stop)	Accounting-Response (start)	Accounting-Response (Interim-Update)	Accounting-Response (Stop)
Acct-Multi-Session-Id(50)	0-1	0-1	0-1	0	0	0
Event-Timestamp(55)	1	1	1	0	0	0
NAS-Port-Type(61)	1	1	1	0	0	0
Tunnel-Type(64)	0-1	0-1	0-1	0	0	0
Tunnel-Medium-Type(65)	0-1	0-1	0-1	0	0	0
Tunnel-Client-Endpoint(66)	0-1	0-1	0-1	0	0	0
Tunnel-Server-Endpoint(67)	0-1	0-1	0-1	0	0	0
Tunnel-Assignment-Id(82)	0-1	0-1	0-1	0	0	0
NAS-Port-Id(87)	1	1	1	0	0	0
Chargeable-User-Identity(89)	0-1	0-1	0-1	0	0	0
Tunnel-Client-Auth-Id(90)	0+	0+	0+	0	0	0
Tunnel-Server-Auth-Id(91)	0+	0+	0+	0	0	0
NAS-IPv6-Address(95)	0-1	0-1	0-1	0	0	0
HW-Input-Committed-Information-Rate(26-2)	0-1	0-1	0-1	0	0	0
HW-Output-Committed-Information-Rate(26-5)	0-1	0-1	0-1	0	0	0
HW-Connect-ID(26-26)	1	1	1	0	0	0

属性	Accounting-Request (Start)	Accounting-Request (Interim-Update)	Accounting-Request (Stop)	Accounting-Response (start)	Accounting-Response (Interim-Update)	Accounting-Response (Stop)
HW-IP-Host-Address(26-60)	1	1	1	0	0	0
HW-Domain-Name(26-138)	1	1	1	0	0	0
HW-AP-Information(26-141)	0-1	0-1	0-1	0	0	0
HW-User-Information(26-142)	0	0	0	0-1	0-1	0
HW-Access-Type(26-153)	0-1	0-1	0-1	0	0	0
HW-User-Extend-Info(26-201)	0-1	0-1	0-1	0	0	0
HW-Reachable-Detect(26-244)	0-1	0-1	0-1	0	0	0
HW-Tariff-Input-Octets(26-247)	0	0-1	0-1	0	0	0
HW-Tariff-Output-Octets(26-248)	0	0-1	0-1	0	0	0
HW-Tariff-Input-Gigawords(26-249)	0	0-1	0-1	0	0	0
HW-Tariff-Output-Gigawords(26-250)	0	0-1	0-1	0	0	0

表 1-15 RADIUS 动态授权报文（CoA/DM）中属性的支持情况

属性号	CoA REQUEST	CoA ACK	CoA NAK	DM REQUEST	DM ACK	DM NAK
User-Name(1)	0-1	0-1	0-1	0-1	0-1	0-1
NAS-IP-Address(4)	0-1	0-1	0	0	0	0
NAS-Port(5)	0-1	0	0	0	0	0

属性号	CoA REQUE ST	CoA ACK	CoA NAK	DM REQUE ST	DM ACK	DM NAK
Framed-IP- Address(8)	0-1	0-1	0-1	0-1	0-1	0-1
Filter-Id(11)	0-1	0	0	0	0	0
Vendor-Specific(26)	0+	0	0	0+	0	0
Session-Timeout(27)	0-1	0	0	0	0	0
Idle-Timeout(28)	0-1	0	0	0	0	0
Termination- Action(29)	0-1	0	0	0	0	0
Calling-Station- Id(31)	0-1	0-1	0-1	0-1	0-1	0-1
Acct-Session-Id(44)	1	1	1	1	1	1
Tunnel-Type(64)	0-1	0	0	0	0	0
Tunnel-Medium- Type(65)	0-1	0	0	0	0	0
Message- Authenticator(80)	0-1	0	0	0	0	0
Tunnel-Private- Group-ID(81)	0-1	0	0	0	0	0
Acct-Interim- Interval(85)	0-1	0	0	0	0	0
NAS-Port-Id(87)	0-1	0	0	0	0	0
Error-Cause(101)	0	0	0+	0	0	0+
HW-Input-Peak- Information- Rate(26-1)	0-1	0	0	0	0	0
HW-Input- Committed- Information- Rate(26-2)	0-1	0	0	0	0	0
HW-Output-Peak- Information- Rate(26-4)	0-1	0	0	0	0	0
HW-Output- Committed- Information- Rate(26-5)	0-1	0	0	0	0	0

属性号	CoA REQUE ST	CoA ACK	CoA NAK	DM REQUE ST	DM ACK	DM NAK
HW-Output-Committed-Burst-Size(26-6)	0-1	0	0	0	0	0
HW-Qos-Data(26-31)	0-1	0	0	0	0	0
HW-Input-Peak-Burst-Size(26-77)	0-1	0	0	0	0	0
HW-Output-Peak-Burst-Size(26-78)	0-1	0	0	0	0	0
HW-User-Policy(26-146)	0-1	0	0	0	0	0
HW-IPv6-Redirect-ACL(26-178)	0-1	0	0	0	0	0

注意事项

VLAN授权注意事项：

服务器上配置了动态VLAN下发功能，则授权信息中含有下发的VLAN属性，设备端在接收到下发的VLAN属性后，会将用户所属的VLAN修改为下发VLAN。

授权下发的VLAN并不改变接口的配置，也不影响接口的配置。但是，授权下发的VLAN的优先级高于用户配置的VLAN，即通过认证后起作用的VLAN是授权下发的VLAN，用户配置的VLAN在用户下线后生效。

动态VLAN下发，使用了以下RADIUS标准属性：

- (064)Tunnel-Type(必须指定为数值13)
- (065)Tunnel-Medium-Type（必须指定为数值6）
- (081)Tunnel-Private-Group-ID

要通过RADIUS服务器正确下发VLAN属性，以上三个属性必须同时使用，而且Tunnel-Type及Tunnel-Medium-Type两个属性的值必须是指定的值。

1.2.4.9 RADIUS 属性禁用和转换功能

不同厂商支持的RADIUS属性集不同，再加上各个厂商都有自己的私有属性，这就造成不同厂商间的RADIUS属性存在不兼容问题，进一步导致不同厂商设备之间发送的RADIUS属性相互无法解析。鉴于以上问题，在对接替换场景中经常使用RADIUS属性禁用功能和RADIUS属性转换功能。

RADIUS 属性禁用功能

RADIUS服务器上定义的RADIUS属性与设备上相比，可能存在属性编号相同、名称相同、但封装的格式或内容不同的情形。此时，可以通过属性禁用功能禁用该属性，之

后，设备接收到RADIUS服务器下发的该属性时，不会解析该属性；设备在发送RADIUS报文到服务器时，也不会封装该属性。

当前，设备支持禁用华为支持的RADIUS属性（即属性名称和编号华为支持），支持禁用发送的或者接收的RADIUS属性。

RADIUS 属性转换功能

属性转换主要是为了兼容不同厂商RADIUS属性定义的差别。例如，华为设备通过私有属性Exec-Privilege（26-29）下发管理员用户的优先级，但某个厂商的接入设备和RADIUS服务器通过属性Login-service（15）下发管理员用户的优先级。在共用一台RADIUS服务器的情况下，用户希望华为设备能够兼容属性Login-service（15）。这种情况在华为设备上配置RADIUS属性转换，源属性为Login-service（15），目的属性为Exec-Privilege（26-29），当设备收到RADIUS认证回应报文解析到属性Login-Service（15）时，会自动当成Exec-Privilege（26-29）属性来处理。

设备支持对发送的或者接收的RADIUS属性进行转换，依据RADIUS属性三元组组成结构（Type、Length和Value）：

- 对于发送方向，如果把属性A转换成属性B，那么设备在发送报文时，属性Type是B，但属性Value是按照属性A的内容与格式封装的；
- 对于接收方向，如果把属性A转换成属性B，那么设备在收到包含属性A的报文时，会把属性A的Value按照属性B的方式来解析，即配置了属性转换后，相当于收到的不是属性A，而是属性B。

设备支持在华为支持的RADIUS属性和不支持的RADIUS属性间进行转换，转换方式如表1-16所示。

说明

- 其他厂家RADIUS属性Type字段长度为1个字节时，设备才支持对其进行转换。
- 源RADIUS属性和目的RADIUS属性的类型一致时，设备才支持对其进行转换。例如：RADIUS属性NAS-Identifier和NAS-Port-Id的类型都是string，两者支持转换；RADIUS属性NAS-Identifier和NAS-Port的类型分别是string和integer，两者不支持转换。
- 不支持转换的RADIUS属性有：CHAP-Challenge、CHAP-Password、Tunnel-Type、Tunnel-Medium-Type、Tunnel-Server-Endpoint、Tunnel-Password、Tunnel-Private-Group-ID、Tunnel-Assignment-Id、Tunnel-Preference、Tunnel-Server-Auth-Id、EAP-Message、Message-Authenticator、NAS-IP-Address、NAS-IPv6-Address、State、Class。

表 1-16 RADIUS 属性转换方式

源RADIUS属性华为是否支持	目的RADIUS属性华为是否支持	支持转换的方向	对应的配置命令（RADIUS服务器模板视图）
支持	支持	发送、接收	<code>radius-attribute translate src-attribute-name dest-attribute-name { receive send access-accept access-request account-request account-response } *</code>

源RADIUS属性华为是否支持	目的RADIUS属性华为是否支持	支持转换的方向	对应的配置命令（RADIUS服务器模板视图）
支持	不支持	发送	<code>radius-attribute translate extend src-attribute-name vendor-specific dest-vendor-id dest-sub-id { access-request account-request } *</code>
不支持	支持	接收	<code>radius-attribute translate extend vendor-specific src-vendor-id src-sub-id dest-attribute-name { access-accept account-response } *</code>

1.2.5 HWTACACS 认证、授权、计费

1.2.5.1 HWTACACS 概述

华为终端访问控制器控制系统协议HWTACACS是在TACACS（RFC 1492）基础上进行了功能增强的安全协议。HWTACACS是一种集中式的、客户端/服务器结构的信息交互协议，使用TCP协议传输，TCP端口号为49。HWTACACS提供的认证、授权和计费服务相互独立，能够在不同的服务器上实现。

HWTACACS协议主要用于采用点对点协议PPP（Point-to-Point Protocol）或虚拟私有拨号网络VPDN（Virtual Private Dial-up Network）方式接入Internet的接入用户以及对设备进行操作的管理用户的认证、授权和计费。

HWTACACS协议与RADIUS协议的相似点包括：

- 结构上都采用客户端/服务器模式。
 - HWTACACS客户端：一般位于网络接入服务器NAS（Network Access Server）上，可以遍布整个网络，负责传输用户信息到指定的HWTACACS服务器，然后根据从服务器返回的信息进行相应处理。
 - HWTACACS服务器：一般运行在中心计算机或工作站上，维护相关的用户认证和网络服务访问信息，负责接收用户连接请求并认证用户，然后给客户端返回所有需要的信息。
- 都使用共享密钥对传输的用户信息进行加密。
- 都有较好的灵活性和可扩展性。

与RADIUS相比，HWTACACS具有更加可靠的传输和加密特性，更加适合于安全控制。HWTACACS协议与RADIUS协议的主要区别如表1-17所示。

表 1-17 HWTACACS 协议与 RADIUS 协议的比较

项目	HWTACACS	RADIUS
数据传输	通过TCP传输，网络传输更可靠。	通过UDP传输，网络传输效率更高。

项目	HWTACACS	RADIUS
加密方式	除了标准的HWTACACS报文头，对报文主体全部进行加密。	只是对认证报文中的密码字段进行加密。
认证和授权	认证与授权分离，使得认证、授权服务可以在不同的安全服务器上实现。例如，可以用一台HWTACACS服务器进行认证，另外一台HWTACACS服务器进行授权。	认证与授权结合，不能分离。
命令行授权	支持对设备上的配置命令进行授权使用。即用户可使用的命令行受到命令级别和AAA授权的双重限制，某一级别的用户输入的每一条命令都需要通过HWTACACS服务器授权，如果授权通过，命令才可以被执行。	不支持对设备上的配置命令进行授权使用。用户登录设备后可以使用的命令行由用户级别决定，用户只能使用级别等于或低于用户级别的命令行。
应用场景	适于进行安全控制。	适于进行计费。

1.2.5.2 HWTACACS 报文介绍

HWTACACS报文与RADIUS报文的格式不同。所有RADIUS报文均采用相同的报文格式，而HWTACACS报文除了具有相同的**报文头**之外，**认证**、**授权**和**计费**报文的格式均不同。

HWTACACS 报文头

HWTACACS报文头长度为12字节，如**图1-15**所示。

图 1-15 HWTACACS 报文头部

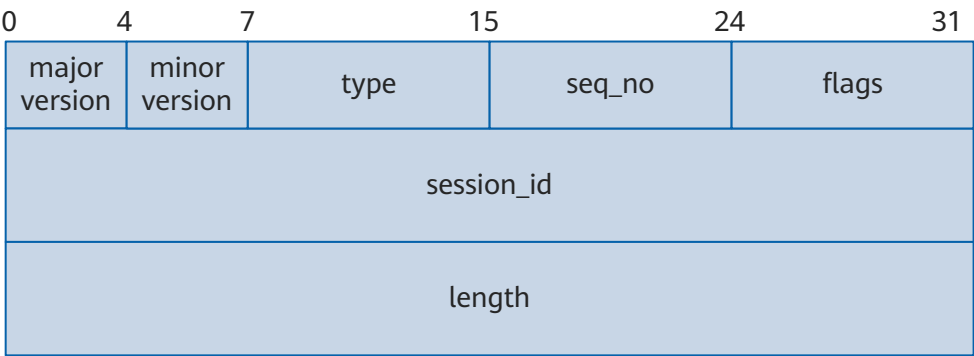


表 1-18 HWTACACS 报文头部中各个字段的含义

字段	含义
major version	HWTACACS协议主版本号，当前版本号为0xc。
minor version	HWTACACS协议次版本号，当前版本号为0x0。
type	HWTACACS协议报文类型，包括认证（0x01）、授权（0x02）和计费（0x03）。
seq_no	对于同一个会话，当前报文的序列号，取值范围为1～254。
flags	报文主体加密标记，目前只支持8位中的第1位，0表示对报文主体加密，1表示不对报文主体加密。
session_id	会话ID，当前会话的唯一标识。
length	HWTACACS报文主体的长度，不包括报文头。

HWTACACS 认证报文格式

HWTACACS认证报文包括三种类型：

- **认证开始报文**Authentication Start：认证开始时，客户端向服务器发送认证开始报文，该报文中包括认证类型、用户名和一些认证数据。
- **认证持续报文**Authentication Continue：客户端接收到服务器回应的认证回应报文后，如果确认认证过程没有结束，则使用认证持续报文响应。
- **认证回应报文**Authentication Reply：服务器接收到客户端发送的认证开始报文或认证持续报文后，向客户端发送的唯一一种认证报文，用于向客户端反馈当前认证的状态。

HWTACACS认证报文的具体格式如下：

- HWTACACS认证开始报文

图 1-16 HWTACACS 认证开始报文格式

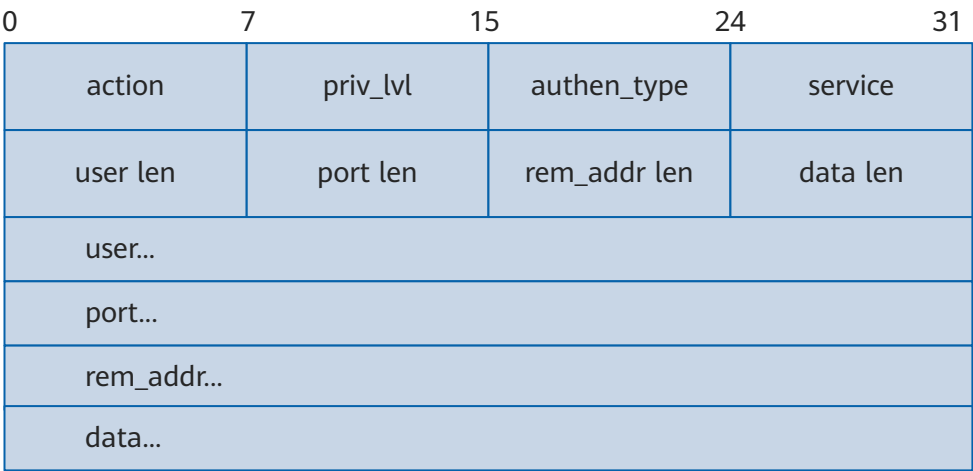


表 1-19 HWTACACS 认证开始报文中各个字段的含义

字段	含义
action	具体的认证操作，目前只支持“认证登录（ 0x01 ）”。
priv_lvl	用户级别，取值范围是0～15。
authen_t ype	认证的类型，目前设备仅支持： ● CHAP（ 0x03 ） ● PAP（ 0x02 ） ● ASCII（ 0x01 ）
service	请求认证的服务类型，当前版本支持PPP（ 0x03 ）、LOGIN（ 0x01 ）、ENABLE（ 0x02 ）、NONE（ 0x00 ）四种服务类型，分别对应PPP用户、管理员用户、管理员用户级别提升认证和其他用户。
user len	登录用户输入的用户名长度。
port len	port字段的长度。
rem_addr len	rem_addr字段的长度。
data len	认证数据区的长度。
user	请求认证的用户名，最大长度为129。
port	请求认证的用户接口名，最大长度为47。 ● 对于管理员用户，该字段是指用户终端接口（例如“console0”、“vty1”等）。例如，Telnet用户的authen_type为ASCII，service为LOGIN，port为vtyx。 ● 对于其他用户，该字段是指用户接入的接口名称。
rem_addr	登录用户的IP地址。

字段	含义
data	认证数据区，根据action和authen_type的不同封装不同的数据。 例如PAP认证时，该字段内容为PAP显式密码。

- HWTACACS认证持续报文

图 1-17 HWTACACS 认证持续报文格式

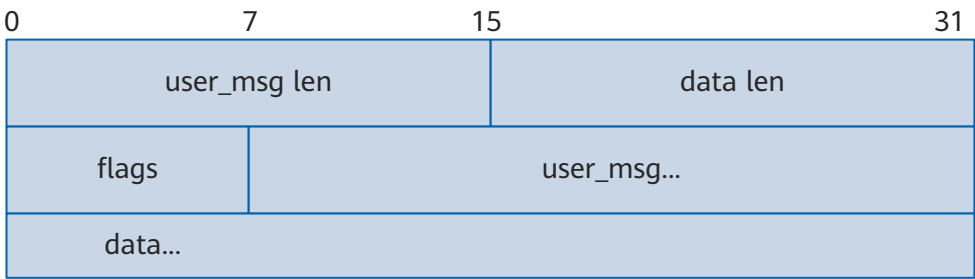


表 1-20 HWTACACS 认证持续报文中各个字段的含义

字段	含义
user_msg len	登录用户输入的字符串长度。
data len	认证数据区的长度。
flags	认证持续标记，0表示认证过程持续，1表示认证过程终止。
user_msg	登录用户输入的字符串，用于回应认证回应报文中的server_msg字段，向服务器提供用户登录时输入的密码。
data	认证数据区，根据action和authen_type的不同封装不同的数据。 例如PAP认证时，该字段内容为PAP显式密码。

- HWTACACS认证回应报文

图 1-18 HWTACACS 认证回应报文格式

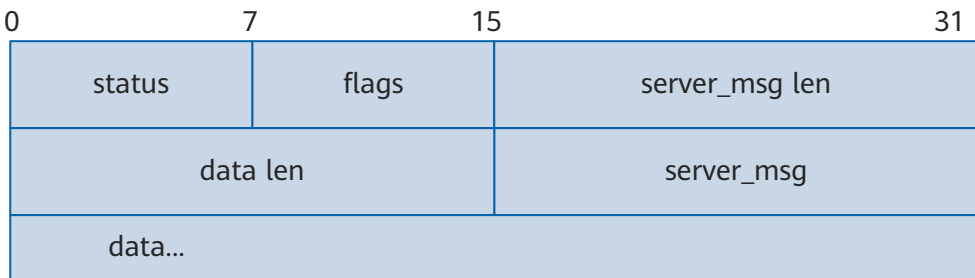


表 1-21 HWTACACS 认证回应报文中各个字段的含义

字段	含义
status	认证的状态，包括： • 认证成功PASS（0x01） • 认证失败FAIL（0x02） • 请求用户信息GETDATA（0x03） • 请求用户名GETUSER（0x04） • 请求密码GETPASS（0x05） • 请求重新发起认证开始RESTART（0x06） • 服务器收到认证报文有误ERROR（0x07） • 服务器要求重新进行认证过程FOLLOW（0x21）
flags	控制客户端是否将用户输入的密码回显。如果该标志位置1，则用户输入的密码不会回显。
server_msg len	server_msg字段的长度。
data len	认证数据区的长度。
server_msg	可选字段，用于服务器将一些附加信息带给用户。
data	认证数据区，用于向客户端提供一些信息。

HWTACACS 授权报文格式

HWTACACS授权报文包括两种类型：

- **授权请求报文**Authorization Request：HWTACACS的认证和授权是分离的，用户可以使用HWTACACS认证而使用其他协议进行授权。如果需要通过HWTACACS进行授权，则客户端向服务器发送授权请求报文，该报文中包括了授权所需的一切信息。
- **授权回应报文**Authorization Response：服务器接收到授权请求报文后，向客户端发送授权回应报文，该报文中包括了授权的结果。

HWTACACS授权报文的具体格式如下：

- HWTACACS授权请求报文

图 1-19 HWTACACS 授权请求报文格式

0	7	15	24	31
authen_method	priv_lvl	authen_type	authen_service	
user len	port len	rem_addr len	arg_cnt	
arg 1 len	arg 2 len	...	arg N len	
user...				
port...				
rem_addr...				
arg 1...				
arg 2...				
...				
arg N...				

说明

priv_lvl字段、authen_type字段、authen_service字段、user len字段、port len字段、rem_addr len字段、port字段、rem_addr字段的含义和HWTACACS认证开始报文一致，此处不再赘述。

表 1-22 HWTACACS 授权请求报文中各个字段的含义

字段	含义
authen_method	指定用户的认证方式，包括： - 没有设置认证方式（0x00） - 不认证（0x01） - 本地认证（0x05） - HWTACACS认证（0x06） - RADIUS认证（0x10）
authen_service	请求认证的服务类型，当前版本支持PPP（0x03）、LOGIN（0x01）和NONE（0x00）三种服务类型，分别对应PPP用户、管理员用户和其他用户。
arg_cnt	授权请求报文中携带的属性数。

字段	含义
argN	指定授权请求报文的属性。包括： - cmd：请求授权的命令行的第一个参数。 - cmd-arg：请求授权的命令行参数。固定格式为“cmd-arg=命令行参数”，最后一个命令行参数后需要再封装一个“cmd-arg=<cr>”结尾。“cmd-arg=命令行参数”的总长度不能超过255个字节，每个命令行参数不能超过247个字节。

- HWTACACS授权回应报文

 说明

server_msg len字段、data len字段和server_msg字段的含义和HWTACACS认证回应报文一致，此处不再赘述。

图 1-20 HWTACACS 授权回应报文格式

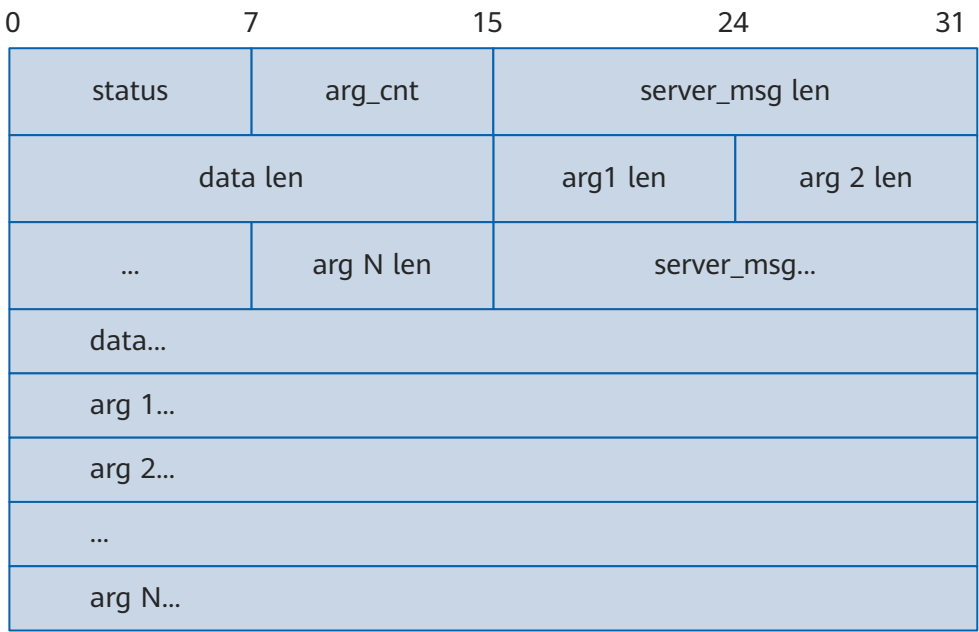


表 1-23 HWTACACS 授权回应报文中各个字段的含义

字段	含义
status	指定用户的授权状态，包括： - 授权通过（0x01） - 授权请求报文中的属性被TACACS服务器修改（0x02） - 授权失败（0x10） - 授权服务器上出现了错误（0x11） - 重新指定授权服务器（0x21）
arg_cnt	授权回应报文中携带的授权属性数。

字段	含义
argN	指定HWTACACS授权服务器下发的授权属性。

HWTACACS 计费报文格式

- HWTACACS计费报文包括两种类型：
- **计费请求报文**Accounting Request：该报文中包括了计费所需的信息。
 - **计费响应报文**Accounting Response：服务器接收并成功记录计费请求报文后，需要回应一个计费响应报文。
- HWTACACS计费报文的具体格式如下：
- HWTACACS计费请求报文

图 1-21 HWTACACS 计费请求报文格式

0	7	15	24	31
flags	authen_method	priv_lvl	authen_type	
authen_service	user len	port len	rem_addr len	
arg_cnt	arg 1 len	arg 2 len	...	
arg N len	user...			
port...				
rem_addr...				
arg 1...				
arg 2...				
...				
arg N...				

说明

authen_method字段、priv_lvl字段、authen_type字段、user len字段、port len字段、rem_addr len字段、port字段、rem_addr字段的含义和HWTACACS授权请求报文一致，此处不再赘述。

表 1-24 HWTACACS 计费请求报文中各个字段的含义

字段	含义
flags	计费类型： - 开始计费（0x02） - 结束计费（0x04） - 实时计费（0x08）
authen_service	请求认证的服务类型，当前版本支持PPP（0x03）、LOGIN（0x01）和NONE（0x00）三种服务类型，分别对应PPP用户、管理员用户和其他用户。
arg_cnt	计费请求报文中携带的属性数。
argN	指定计费请求报文的属性。

- HWTACACS计费回应报文

图 1-22 HWTACACS 计费回应报文格式

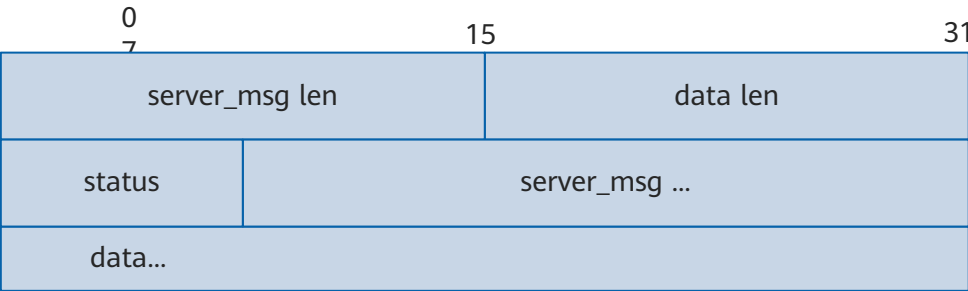


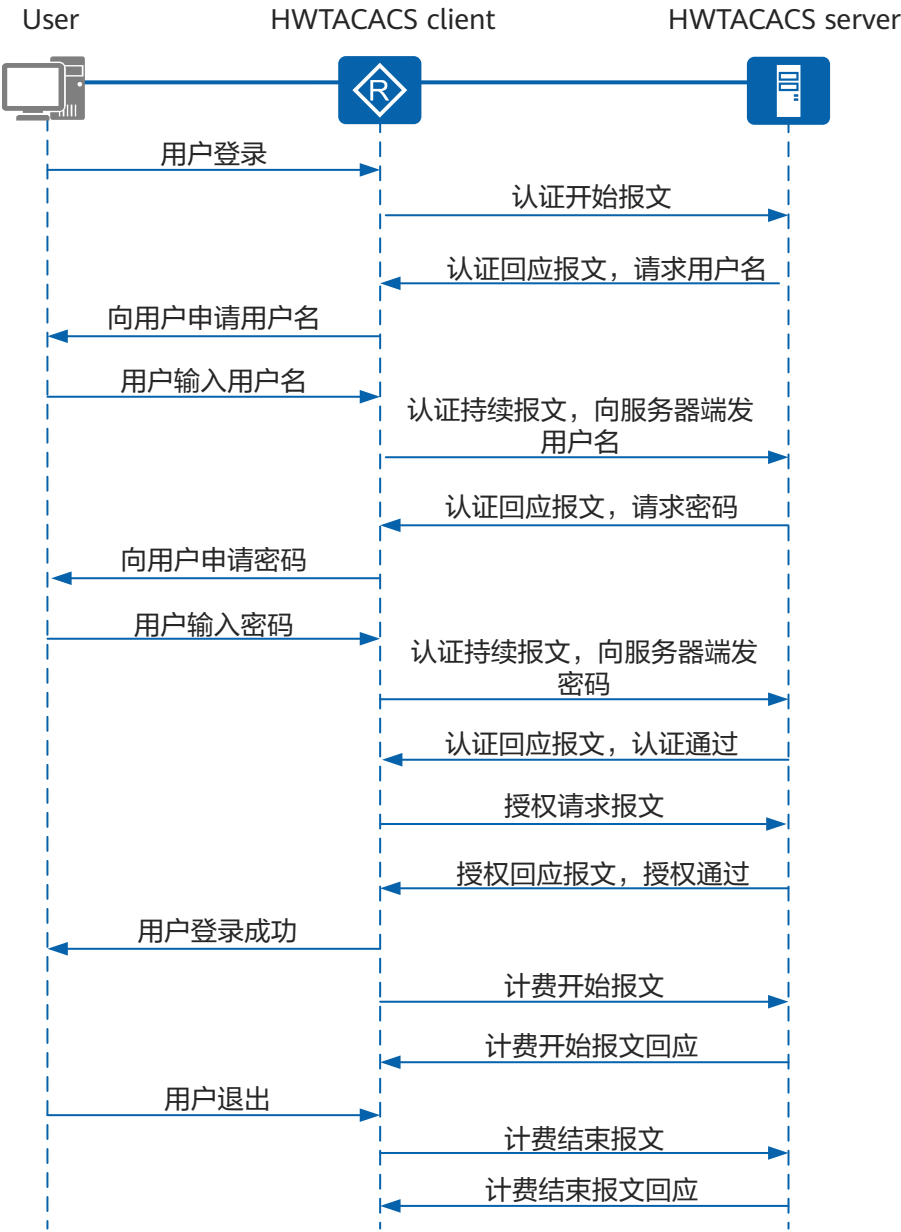
表 1-25 HWTACACS 计费回应报文中各个字段的含义

字段	含义
server_msg len	server_msg字段的长度。
data len	data字段的长度。
status	指定计费状态： - 计费成功（0x01） - 计费失败（0x02） - 计费无回应（0x03） - 服务器要求重新进行计费过程（0x21）
server_msg	指定计费服务器带给客户端的信息。
data	服务器提供给管理员的信息。

1.2.5.3 HWTACACS 认证、授权、计费流程

下面以Telnet用户为例，说明使用HWTACACS对用户进行认证、授权和计费的过程。基本消息交互流程图如图1-23所示。

图 1-23 HWTACACS 的基本消息交互流程图



在整个过程中的基本消息交互流程如下：

1. Telnet用户请求登录设备。
2. HWTACACS客户端收到请求之后，向HWTACACS服务器发送认证开始报文。
3. HWTACACS服务器发送认证回应报文，请求用户名。

4. HWTACACS客户端收到回应报文后，向用户询问用户名。
5. 用户输入用户名。
6. HWTACACS客户端收到用户名后，向HWTACACS服务器发送认证持续报文，其中包括了用户名。
7. HWTACACS服务器发送认证回应报文，请求密码。
8. HWTACACS客户端收到认证回应报文，向用户询问密码。
9. 用户输入密码。
10. HWTACACS客户端收到密码后，向HWTACACS服务器发送认证持续报文，其中包括了密码信息。
11. HWTACACS服务器发送认证回应报文，指示用户通过认证。
12. HWTACACS客户端向HWTACACS服务器发送授权请求报文。
13. HWTACACS服务器发送授权回应报文，指示用户通过授权。
14. HWTACACS客户端收到授权回应报文，向用户输出设备的配置界面。
15. HWTACACS客户端向HWTACACS服务器发送计费开始请求报文。
16. HWTACACS服务器发送计费开始回应报文，指示计费开始请求报文已经收到。
17. 用户请求断开连接。
18. HWTACACS客户端向HWTACACS服务器发送计费结束请求报文。
19. HWTACACS服务器发送计费结束回应报文，指示计费结束请求报文已经收到。

 说明

HWTACACS协议与其他厂商支持的TACACS+协议都实现了认证、授权、计费的功能。HWTACACS和TACACS+的认证流程与实现方式是一致的，HWTACACS协议能够完全兼容TACACS+协议。

1.2.5.4 HWTACACS 属性

在HWTACACS授权或计费报文中，argN字段携带了服务器下发给用户或用户传输给服务器的信息。

HWTACACS 属性

表1-26描述了设备支持的HWTACACS属性，对于不在该表内的属性，设备不对属性进行解析，直接忽略具体的属性内容。

表 1-26 常用 HWTACACS 属性

属性名	属性说明
acl	授权的ACL ID。
addr	用户的IP地址。
autocmd	用户登录到设备后自动执行的命令。
bytes_in	设备接收到的流量。其中，K、M、G分别表示流量单位KByte，MByte，GByte，如果没有，则单位是Byte。
bytes_out	设备发送的流量。其中，K、M、G分别表示流量单位KByte，MByte，GByte，如果没有，则单位是Byte。

属性名	属性说明
callback-line	回呼号码，即服务器传递过来可以显示给用户的信息，例如移动电话号码等。
cmd	在shell上执行的命令行，最大长度为251字符。命令行记录时封装的是完整的命令行，命令行授权时封装的是命令行的第一个关键字。
cmd-arg	命令行授权请求时，请求授权的命令行参数。最后一个参数命令行参数后需要再封装一个cmd-arg=<cr>结尾。
disc_cause	下线原因，仅结束计费请求报文支持该属性。包括： ● 用户主动下线（1） ● 数据中断（2） ● 业务中断（3） ● 闲置切断（4） ● 会话超时（5） ● 管理员要求下线（7） ● NAS故障（9） ● NAS要求下线（10） ● 端口停用（12） ● 用户信息有误（17） ● 主机主动下线（18）
disc_cause_ext	扩展的下线原因，仅结束计费请求报文支持该属性。包括： ● 未知原因（1022） ● EXEC终端终止连接（1020） ● 已经在线的其他telnet用户强制此用户下线（1022） ● 远端没有IP地址，导致用户不能切换到SLIP/PPP客户端（1023） ● PPP PAP认证失败（1042） ● PPP收到远端的Terminate报文（1045） ● 上层要求关闭用户的PPP连接（1046） ● PPP握手失败（1063） ● 会话超时（1100）
dnaverage	下行平均速率，单位是bit/s。
dnpeak	下行峰值速率，单位是bit/s。
dns-servers	主DNS服务器的IP地址。
elapsed_time	用户的在线时长，单位是秒。
ftplib	FTP用户的初始目录。
gw-password	隧道密码，字符串类型，长度范围是1～248。如果所包含的属性值超出了允许的设置范围则仅取前248个字符。

属性名	属性说明
idletime	空闲切断时间，即服务器会自动切断空闲切断时间内没有进行任何操作的用户。 说明 FTP用户不支持该属性。
l2tp-hello-interval	L2TP Hello报文的间隔时间，目前设备尚不支持该属性。
l2tp-hidden-avp	L2TP的隐藏属性值对AVP（Attribute Value Pair），目前设备尚不支持该属性。
l2tp-nosession-timeout	L2TP无会话时切断时间，即无会话时，L2TP隧道将会该时间间隔后被拆除。目前设备尚不支持该属性。
l2tp-group-num	L2TP组号，只有下发了该属性，其他的L2TP属性才能生效，如果没有下发该属性，其他L2TP属性都会被忽略。
l2tp-tos-reflect	L2TP的TOS的值，目前设备尚不支持该属性。
l2tp-tunnel-authen	是否进行L2TP的隧道认证。0表示不进行隧道认证，1表示进行隧道认证。
l2tp-udp-checksum	L2TP的UDP包的检验和。
nocallback-verify	回呼之后不需要验证。
nohangup	设备是否自动切断用户的连接，取值为true或者false。该属性依附于autocmd属性，在配置了autocmd参数后，用户执行完autocmd的命令后是否将用户切断。true表示不切断，false表示切断。
paks_in	设备接收到的包数，单位是个。
paks_out	设备发送的包数，单位是个。
priv-lvl	用户的级别。
protocol	协议类型，是业务类型的一个子集，针对ppp、connection业务类型生效。目前支持“pad”、“telnet”、“ip”和“vpdn”四种协议类型。 - 当业务类型为connection时，协议类型可以是“pad”或者“telnet”； - 当业务类型是ppp时，协议类型可以是“ip”或者“vpdn”； - 如果为其它业务类型，则不会封装该属性。
task_id	任务ID，对于同一任务，其开始和结束记录的task_id必须相同。
timezone	当地时区。
tunnel-id	建立隧道时的隧道本端用户名，字符串形式，长度范围是1～29。如果所包含的属性值超出了允许的设置范围则仅取前29个字符。

属性名	属性说明
tunnel-type	将要建立的隧道类型。目前只支持L2TP类型的隧道，对应的tunnel-type是3。
service	业务类型，标识当前计费或授权的业务。
source-ip	隧道本端IP的地址。
upaverage	上行平均速率，单位是bit/s。
uppeak	上行峰值速率，单位是bit/s。

HWTACACS 属性在报文中的支持情况

按照报文类型划分，HWTACACS授权报文可以分为授权请求报文和授权回应报文。但在实际使用过程中，HWTACACS授权可以划分为EXEC用户授权、命令行授权和接入用户授权三种，不同类型的授权报文中使用的属性不完全相同，具体请参见表1-27。

- EXEC授权：通过HWTACACS服务器对telnet、terminal、SSH和FTP登录的管理用户进行权限控制。
- 命令行授权：用户执行每条命令行时均进行权限控制，只有授权通过后可以执行该命令，否则不能执行。
- 接入用户授权：通过HWTACACS服务器对802.1X、Portal等NAC接入用户进行权限控制。

按照报文类型划分，HWTACACS计费报文可以分为计费请求报文和计费回应报文。但在实际使用过程中，根据连接类型的不同，HWTACACS计费可以划分为网络计费、连接计费、EXEC计费、系统计费和命令计费五种类型。不同类型的计费报文中使用的属性不完全相同，具体请参见表1-28。

- 网络计费：适用于PPP等普通用户接入网络的场景。例如，PPP用户初始接入时发送开始计费报文，用户在线过程中定时发送实时计费报文，用户下线时发送结束计费报文。
- 连接计费：适用于当用户将设备作为Telnet或者FTP的客户端登录到服务器端的场景。用户与设备建立连接后，可以输入命令建立与远程服务器的连接并访问远程主机上的文件。当登录到远程服务器时发送开始计费报文，退出时发送结束计费报文。
- EXEC计费：适用于用户通过Telnet或者FTP等方式登录到设备的场景。用户初始登录时发送开始计费报文，用户在线过程中发送实时计费报文，用户退出时发送结束计费报文。
- 系统计费：适用于用户对网络进行故障诊断时的场景。通过在服务器上记录系统级事件，可以帮助管理员用户根据服务器上的记录信息进行故障定位。
- 命令计费：当管理员用户在设备上执行任意命令时，可以通过命令结束计费报文把该用户输入的命令上报给HWTACACS服务器，以便服务器对用户的操作进行记录。

说明

- Y：表示该类型报文支持该属性。
- N：表示该类型报文不支持该属性。

表 1-27 HWTACACS 授权报文中属性的支持情况

属性	命令行授权请求报 文	EXEC授权回应报 文	接入用户授权 回应报文
acl	N	Y	N
addr	N	N	Y
addr-pool	N	N	Y
autocmd	N	Y	N
callback-line	N	Y	Y
cmd	Y	N	N
cmd-arg	Y	N	N
dnaverage	N	N	Y
dnpeak	N	N	Y
dns-servers	N	N	Y
ftplib	N	Y	N
gw-password	N	N	Y
idletime	N	Y	N
ip-addresses	N	N	Y
l2tp-group-num	N	N	Y
l2tp-tunnel-authen	N	N	Y
nocallback-verify	N	Y	N
nohangup	N	Y	N
priv-lvl	N	Y	N
source-ip	N	N	Y
tunnel-type	N	N	Y
tunnel-id	N	N	Y
upaverage	N	N	Y

表 1-28 HWTACACS 计费报文中属性的支持情况

属性	网络计费开始请求报文	网络计费结束请求报文	网络计费实时请求报文	连接计费开始请求报文	连接计费结束请求报文	EXEC计费开始请求报文	EXEC计费结束请求报文	EXEC计费实时请求报文	系统计费结束请求报文	命令计费停止计费报文
addr	Y	Y	Y	Y	Y	N	N	N	N	N
bytes_in	N	Y	Y	N	Y	N	Y	Y	N	N
bytes_out	N	Y	Y	N	Y	N	Y	Y	N	N
cmd	N	N	N	Y	Y	N	N	N	N	Y
disc_cause	N	Y	N	N	N	N	Y	Y	N	N
disc_cause_ext	N	Y	N	N	N	N	Y	Y	N	N
elapsed_time	N	Y	Y	N	Y	N	Y	Y	Y	N
paks_in	N	Y	Y	N	Y	N	Y	Y	N	N
paks_out	N	Y	Y	N	Y	N	Y	Y	N	N
priv-lvl	N	N	N	N	N	N	N	N	N	Y
protocol	Y	Y	Y	Y	Y	N	N	N	N	N
service	Y	Y	Y	Y	Y	Y	Y	Y	Y	Y
task_id	Y	Y	Y	Y	Y	Y	Y	Y	Y	Y
timezone	Y	Y	Y	Y	Y	Y	Y	Y	Y	Y
tunnel-id	N	N	N	N	N	N	N	N	N	N
tunnel-type	Y	N	N	N	N	N	N	N	N	N

1.2.6 HACA 认证、授权、计费

1.2.6.1 HACA 概述

日益发展的中小型企业具有网络规模较小、并发上线用户数量少、网络部署站点分散等特点。面对此类用户，华为提出“云管理网络解决方案”，通过公有云向广大中小型企业用户提供服务，可实现多租户的统一管理、网络设备的即插即用、网络业务批量

部署等功能。与传统的网络架构和部署方式相比，该方案不仅网络部署周期短、维护成本低，而且网络扩展性较好。

云管理场景下用户准入认证主要采用Portal认证。由于认证服务器部署在互联网中，设备到服务器之间可能需要穿越NAT，而普通的Portal认证采用Portal协议无法穿越NAT，因此采用华为敏捷云认证HACA（Huawei Agile Cloud Authentication）使设备与服务器之间建立连接，然后进行Portal认证。当前仅支持iMaster NCE-Campus作为HACA服务器。

HACA协议是基于移动互联网HTTP 2.0协议，目前HACA支持情况如下：

- 支持Portal认证或MAC优先的Portal认证。
- 不支持管理员、IPSec、SSL VPN、IP session、PPPoE、L2TP、VM、802.1X、独立MAC认证。
- 不支持有线用户接入。

1.2.6.2 HACA 业务报文类型介绍

业务报文内容记录HACA服务器与设备进行交互消息，业务报文类型（msgType）包括如下：

表 1-29 HACA 业务报文类型

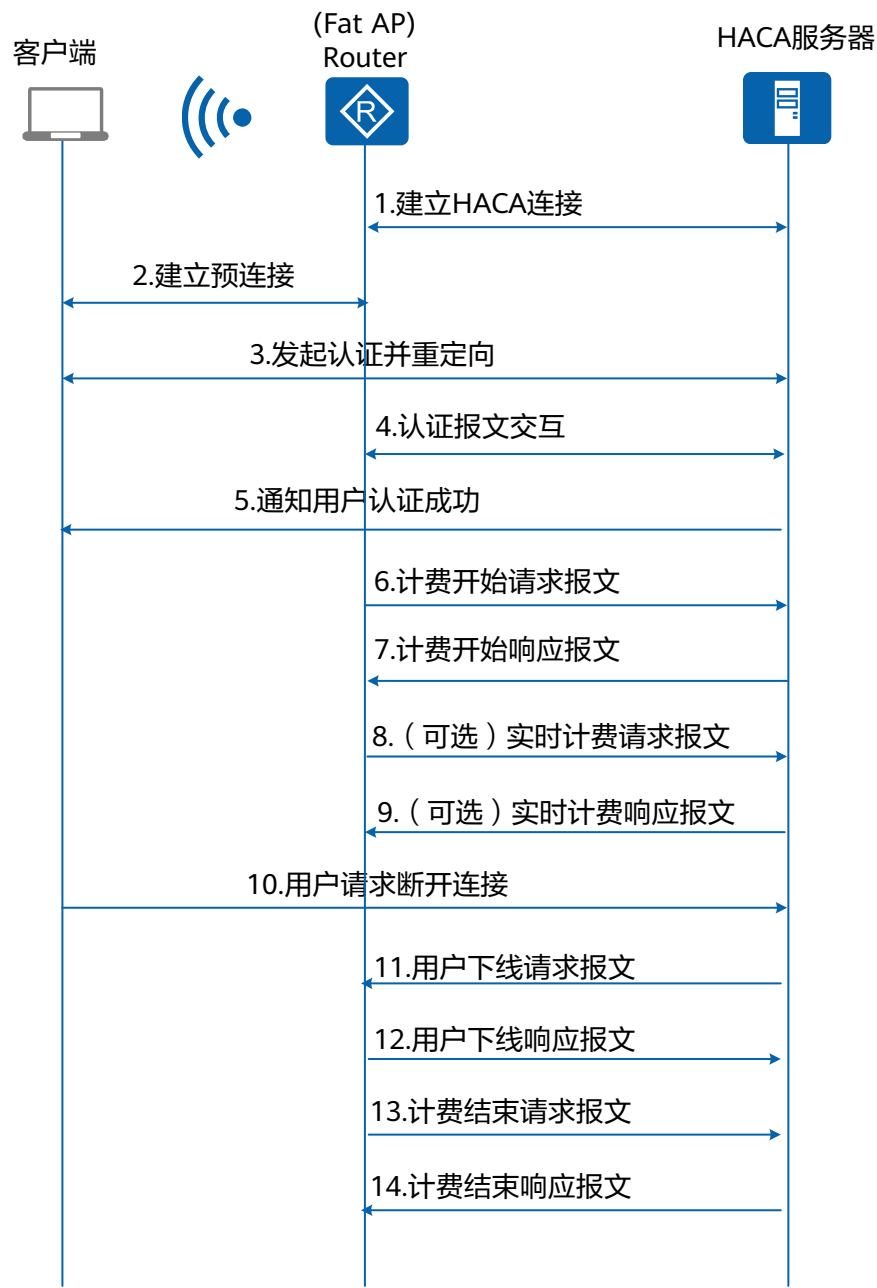
业务报文类型	msgType	说明
注册请求报文	1	设备与HACA服务器建立HTTP 2.0长连接后，发送注册请求报文给HACA服务器，将设备信息注册到服务器上。
注册响应报文	2	HACA服务器给设备发送注册响应报文，表示长连接建立完成，可以进行业务报文收发。
认证请求报文	3	设备发送给HACA服务器，HACA服务器根据该报文中携带的用户信息判断是否允许接入。
认证响应报文	4	HACA服务器对设备发送的认证请求报文的响应报文。如果认证请求报文中的所有属性都可以接受（即认证通过），则发送该类型报文。设备收到此报文后，认证用户才能认证通过并被赋予相应的权限。
主动授权响应报文	5	设备对HACA服务器发送的主动授权报文的响应报文，同时设备会更改用户的权限。
主动授权请求报文	6	HACA服务器在用户认证成功后，发送主动授权报文给设备。
计费请求报文	7	设备在用户开始访问网络资源时，向HACA服务器发送计费请求报文。
计费响应报文	8	HACA服务器接收并成功记录计费请求报文后，需要回应一个计费响应报文。
下线通知报文	9	设备通过HACA服务器下线时，服务器不需要响应；如果是计费用户，设备需要携带计费信息。

业务报文类型	msgType	说明
下线请求报文	11	设备主动触发用户下线时，由设备发送下线请求报文给HACA服务器将指定用户下线；HACA服务器触发用户下线时，发送该消息通知设备将指定用户下线。
下线请求响应报文	12	设备主动触发用户下线时，HACA服务器对设备发送的下线请求报文的响应报文；HACA服务器触发用户下线时，设备对服务器发送的下线请求报文的响应报文，同时释放相关授权表项。
用户同步请求报文	13	用于解决HACA服务器与设备之间由于异常导致用户信息不一致，通过周期性同步，保证设备与HACA服务器上用户信息的一致性。设备触发的HACA用户同步功能，由设备向HACA服务器发送同步用户请求；HACA服务器触发HACA用户同步功能时，由服务器向设备发送同步用户请求。
用户同步响应报文	14	设备触发的HACA用户同步功能时，HACA服务器对设备发送的用户同步请求报文的响应报文；HACA服务器触发HACA用户同步功能时，设备对服务器发送的用户同步请求报文的响应报文。
动态授权请求报文	15	当管理员需要更改某个在线用户的权限时（例如，管理员不希望用户访问某个网站），可以通过HACA服务器发送一个动态授权请求报文给设备，使设备修改在线用户的权限。
动态授权响应报文	16	如果设备成功更改了用户的权限，则设备回应动态授权响应报文给HACA服务器。

1.2.6.3 HACA 认证、授权、计费流程

iMaster NCE-Campus作为HACA服务器部署在云端实现外置Portal服务器以及认证计费服务器。路由器（FAT AP形态）产品作为接入设备供无线终端接入，同时作为无线用户的认证点，与HACA服务器完成用户认证上线功能。用户的授权信息由HACA服务器指定，用户认证通过后，HACA服务器会授予用户访问网络访问权限。HACA认证、授权、计费流程如图1-24所示。

图 1-24 HACA 的认证、授权、计费流程图



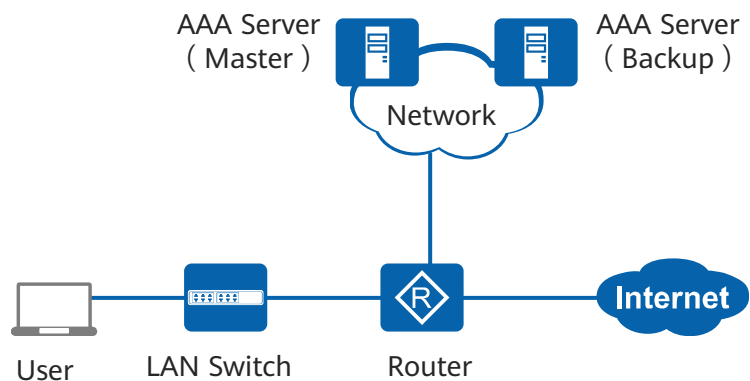
1. 设备与HACA服务器通过HTTP 2.0协议与HACA服务器建立长连接并注册设备信息。
2. 在认证之前客户端与设备之间建立起预连接。
3. 客户端通过HTTP协议发起认证请求。HACA服务器提供Web页面供用户输入用户名和密码来进行认证。
4. 接入设备与HACA服务器之间进行认证报文的交互。
5. 用户认证成功后，HACA服务器主动发送授权报文授予用户网络访问权限。
6. 用户开始访问网络后，接入设备向HACA服务器发送计费开始请求报文。

7. HACA服务器向接入设备发送计费开始响应报文，并开始计费。
8. （可选）在使能实时计费功能的情况下，接入设备会定时向HACA服务器发送实时计费请求报文，以避免因付费用户异常下线导致的不合理计费。
9. （可选）HACA服务器返回实时计费响应报文，并实时计费。
10. 用户发起下线请求。
11. HACA服务器向接入设备发送用户下线请求报文。
12. 接入设备向HACA服务器返回用户下线响应报文。
13. 接入设备向HACA服务器提交计费结束请求报文。
14. HACA服务器返回计费结束响应报文，并停止计费。

1.3 AAA 应用场景

通过 AAA 为上网用户提供认证、授权和计费

图 1-25 通过 AAA 为上网用户提供认证、授权和计费



如图1-25所示，Router作为目的网络接入服务器。用户需要通过服务器的远端认证才能通过建立连接，该网络中的用户需要访问Internet资源。为了保证网络的安全性，企业管理员希望控制用户对于Internet的访问。

通过在Router上配置AAA，实现Router与AAA服务器的对接，可以由AAA服务器对用户进行统一管理。用户在客户端上输入用户名和密码后，Router可以接收到用户的用户名和密码等认证信息并将用户信息发送给AAA服务器，由AAA服务器对其进行认证。如果认证通过，则用户可以开始访问Internet。在用户访问过程中，AAA服务器还可以记录用户使用网络资源的情况。

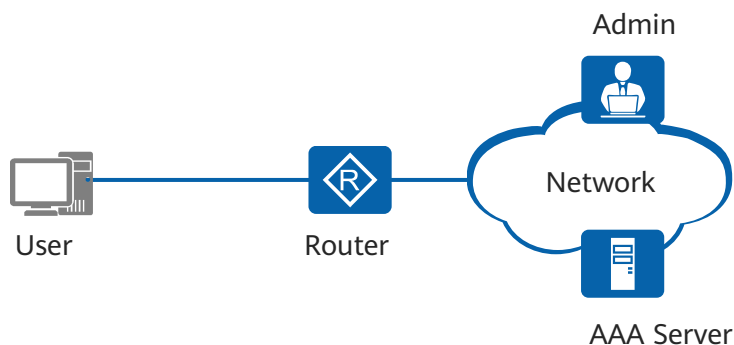
为了提高可靠性，可以部署两台AAA服务器，并在Router上进行相应配置实现AAA服务器的主备备份，主服务器发生故障时，备服务器可以接替主服务器工作，保证用户业务不会中断。

通过 AAA 对管理用户进行认证和授权

如图1-26所示，管理用户（Administrator）与Router建立连接，对Router进行管理、配置和维护。

在Router上配置AAA后，当管理用户登录Router时，Router将管理用户的用户名和密码等信息发送给AAA服务器，由AAA服务器来进行统一认证，同时记录这些用户的操作行为。

图 1-26 通过 AAA 对管理用户进行认证和授权



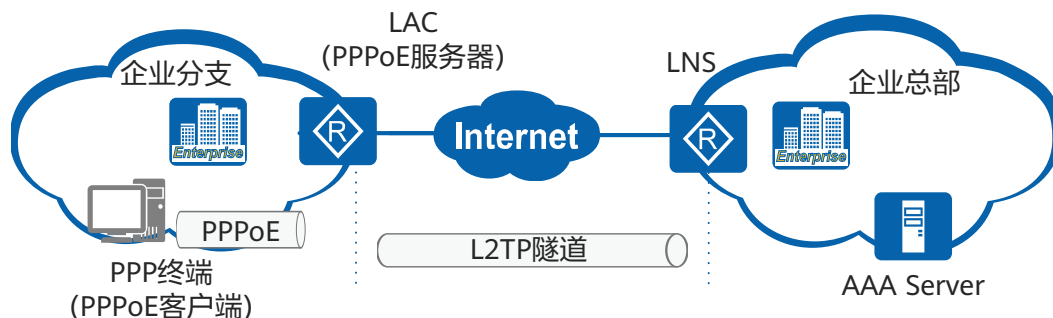
通过 AAA 对 VPN 用户进行认证、授权和计费

AAA同样可以应用在VPN中，例如，AAA可以为L2TP VPN中的PPP拨号用户提供认证、授权和计费。

如图1-27所示，企业总部在其他城市设有分支机构，分支机构内部使用以太网络。分支用户需要和总部用户建立VPDN连接，在分支和总部之间部署L2TP，其中分支机构没有拨号网络，将分支的网关部署为PPPoE服务器，使分支用户的PPP拨号可以通过以太网传输，同时分支网关也作为LAC，和总部建立L2TP隧道。企业总部的网关部署为LNS，为分支用户提供接入服务，实现分支用户和总部网关之间的L2TP连接。

由于LNS需要对接入用户进行管理，可以通过在LNS上配置AAA认证，实现LNS与AAA服务器的对接。当LNS接收到拨号用户的认证信息后，LNS将信息发送给AAA服务器，由AAA服务器来进行统一管理。

图 1-27 通过 AAA 对 VPN 用户进行认证、授权和计费

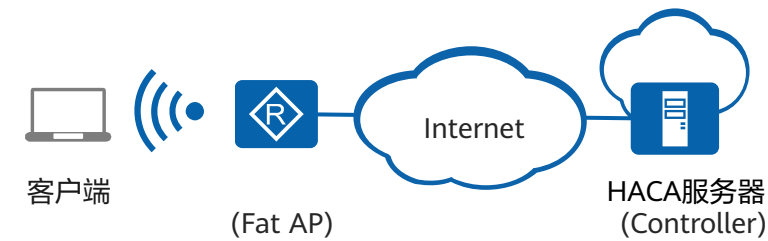


通过 HACA 准入授权用户上线

HACA仅支持MAC优先的Portal认证场景，如图1-28所示，Router作为FAT AP，提供用户无线接入Internet网络。将Controller服务器作为HACA服务器，部署在云端实现

外置Portal服务器以及认证、计费服务器的功能。Router通过HTTP 2.0协议与HACA服务器建立长连接并注册设备信息，在进行Portal认证时，Router与HACA服务器之间的报文通过HTTP 2.0长连接通道进行交互。

图 1-28 通过 HACA 准入授权用户上线



1.4 AAA 配置注意事项

涉及网元

表 1-30 本特性涉及网元

角色	产品	说明
AAA服务器	华为公司或第三方公司的AAA服务器产品。	负责对用户进行认证、计费 and 授权。

License 支持

AAA是设备的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

仅AR720和AR730不支持HACA。

特性依赖和限制

- 为了避免设备和RADIUS服务器或HWTACACS服务器之间的安全传输风险，建议设备和服务器之间的通信网络部署在一个安全域中。
- 如果使用`authentication-mode`命令配置认证方式为不认证，则当用户上线时，用户输入任意的用户名和密码后都会认证成功。因此，为保护设备或网络安全，建议开启认证方式，保证用户经过认证后才可以访问设备或网络。
- 缺省情况下，全局默认普通域default和全局默认管理域default_admin域内都绑定了default计费方案，修改default计费方案会同时影响这两个域的配置，请谨慎操作，以免造成用户计费失败。
- RADIUS认证对接入类型为L2TP的用户不生效。

- 设备的管理口不支持收发RADIUS报文。
- 如果设备全局配置了默认VPN实例，则需要在VPN实例内配置路由互通，并将HWTACACS服务器绑定的源IP地址加入到VPN实例中。建议用户通过执行**undo set net-manager vpn-instance**命令取消全局已配置的默认VPN实例。
- 设备通过TACACS计费报文上报管理员在设备上通过SSH、Telnet、WEB网管命令行界面执行过的命令，因此设备需要配置TACACS计费服务器。
- 设备支持通过TACACS授权报文授权SSH、Telnet登录的管理员执行HWTACACS服务器的命令行，WEB网管命令行界面只能通过登录管理员的级别限制执行命令行的权限，不支持HWTACACS服务器授权。

1.5 AAA 缺省配置

AAA的常用缺省配置如表1-31所示。

表 1-31 AAA 的缺省配置

参数	缺省值
本地用户	• 名称：admin • 密码：您可以在《AR路由器 缺省帐号与密码》（企业网、运营商）文档中获取各种缺省帐号与密码信息。获取该文档需要权限，如需升级权限，请查看网站帮助。 • 接入方式：SSH、HTTP（用于Web网管方式登录设备）
全局默认普通域	default：默认绑定认证方案radius和计费方案default、未绑定授权方案。
全局默认管理域	default_admin：默认绑定认证方案default和计费方案default、未绑定授权方案。
认证方案	default：默认认证方式为本地认证。 radius：默认认证方式为RADIUS认证。
授权方案	default：默认授权方式为本地授权。
计费方案	default：默认不计费。

1.6 AAA 配置任务概览

理论上，设备支持多种方式的认证、授权、计费的组合，比如本地认证、本地授权和RADIUS计费。

实际应用中，常见的是每种方式的单独应用，如表1-32所示。此外，设备还支持一个方案中使用多种协议模式，比如本地认证还常用于RADIUS认证和HWTACACS认证的备份认证方案，本地授权作为HWTACACS授权的备份授权方案。

表 1-32 AAA 配置任务概览

场景	概述	对应任务
本地认证和授权	如果需要对用户进行认证或授权，但是在网络中没有部署 RADIUS服务器和HWTACACS服务器，那么可以采用本地方式进行认证和授权。本地方式进行认证和授权的优点是速度快，可以降低运营成本；缺点是存储信息量受设备硬件条件限制。 管理用户常采用本地认证和授权方式。	1.7 配置采用本地方式进行认证和授权
RADIUS认证、授权和计费	采用RADIUS方式进行认证、授权、计费可以防止非法用户对网络的攻击，常应用在既要求较高安全性又要求控制远程用户访问权限的网络环境中。	1.8 配置采用RADIUS方式进行认证、授权和计费
HWTACACS认证、授权和计费	采用HWTACACS方式进行认证、授权、计费可以防止非法用户对网络的攻击，还支持对命令行进行授权。与RADIUS相比，HWTACACS具有更加可靠的传输和加密特性，更加适合于安全控制。	1.9 配置采用HWTACACS方式进行认证、授权和计费
HACA认证、授权、计费	HACA协议常用于云管理场景。HACA协议是基于移动互联网 HTTP 2.0协议,且HACA仅支持 MAC优先的Portal认证场景。	1.10 配置采用HACA方式进行认证

1.7 配置采用本地方式进行认证和授权

本地方式进行认证和授权

在本地方式进行认证和授权中，用户信息（包括本地用户的用户名、密码和各种属性）都配置在设备上。本地方式进行认证和授权的优点是速度快，可以降低运营成本，缺点是存储信息量受设备硬件条件限制。

配置流程

配置	步骤	说明
配置本地服务器	配置本地用户	创建本地用户，设备根据创建的用户信息对本地用户进行认证。

配置	步骤	说明
	配置授权规则	在设备上创建相应的授权规则，本地授权时可以根据创建的授权规则对用户授权。
配置并应用AAA方案	配置AAA方案	配置认证、授权、计费方案。
	（可选）配置业务方案	业务方案中也可以配置用户的授权信息。
	在域下应用AAA方案	创建好的AAA方案和业务方案需要绑定到用户所属域下才能生效。
-	检查配置结果	检查配置是否正确。

1.7.1 配置本地服务器

背景信息

AAA认证、授权可以在NAS设备上完成，也可以交由服务器完成。如果在NAS上完成AAA认证和授权，则相当在NAS上配置一个本地的AAA服务器。本地认证的优点是速度快，可以为运营降低成本，缺点是存储信息量受设备硬件条件限制。

配置本地服务器，需要在设备上配置用户的认证和授权信息，包括配置本地用户和配置本地授权两个步骤。

1.7.1.1 配置本地用户

背景信息

配置本地用户时，可以配置本地用户允许建立的连接数目、本地用户级别、闲置切断时间以及本地用户上线时间等功能，同时支持本地用户修改密码功能。

说明

- 为充分保证设备安全，请用户不要关闭密码复杂度检查功能，并定期修改密码。
- 更改本地帐号的权限（密码、接入类型、FTP目录、级别等）后，已经在线的用户权限不会被更改，新上线的用户则以新的权限为准。
- 本地用户的接入类型分为以下两类：
 - 管理类：包括ftp、http、ssh、telnet、x25-pad和terminal。
 - 普通类：包括8021x、bind、ppp、sslvpn和web。
- 登录方式为Telnet和FTP时存在安全风险，建议使用STelnet和SFTP，此时，用户的接入类型配置为SSH。

缺省情况下，HTTP采用随机生成的自签名证书支持HTTPS。由于自签名证书存在安全风险，因此建议用户替换为官方授信的数字证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**aaa**，进入AAA视图。

步骤3 创建本地用户。

步骤	命令	说明
（可选） 使能对密码进行复杂度检查功能	user-password complexity-check [three-of-kinds]	缺省情况下，设备对密码进行复杂度检查。用户设置的密码至少包含“大写字母、小写字母、数字和特殊字符”中的两种，才能通过密码复杂度检查。
创建本地用户名和密码(选择一种方式创建本地用户名和密码)	local-user <i>user-name</i> password	缺省情况下：您可以在《AR路由器缺省帐号与密码》（ 企业网、运营商 ）文档中获取各种缺省帐号与密码信息。获取该文档需要权限，如需升级权限，请查看网站帮助。 本命令为交互式命令，当用户输入密码时，直接以明文形式输入存在安全风险，建议用户以交互式方式输入。 如果用户名中带域名分隔符（如“@”、“ ”、“%”等符号），并且没有执行命令 domainname-parse-direction right-to-left 设置域名解析方向，则认为分隔符前面的部分是纯用户名，后面部分是域名。如果没有分隔符，则整个字符串为用户名，普通用户默认到 default 域认证，管理用户默认到 default_admin 域进行认证。
	local-user <i>user-name</i> password { cipher irreversible-cipher } <i>password</i>	
配置本地用户的允许接入类型	local-user <i>user-name</i> service-type { 8021x bind ftp http ppp ssh sslvpn telnet terminal web x25-pad } *	缺省情况下，本地用户关闭所有的接入类型。 如果为Portal接入用户，则配置的接入类型为 web 。 配置本地用户的接入类型前，如果用户已经存在，需注意： - 如果密码使用的是不可逆加密算法，则只允许配置管理类的接入类型。 - 如果密码使用的是可逆加密算法，则允许配置普通类或者管理类的接入类型，不允许配置普通类与管理类的混合类接入类型，并且当配置为管理类的接入类型时，加密算法自动转换成不可逆加密算法。

步骤	命令	说明
（可选） 为本地用户分配固定的IP地址	local-user <i>user-name</i> bind-ip <i>ip-address</i>	缺省情况下，系统没有为本地用户分配固定的IP地址。

步骤4 （可选）配置用户级别、所属用户组、接入时间段、闲置切断功能及可建立的连接数目。

步骤	命令	说明
配置本地用户级别	local-user <i>user-name</i> privilege level <i>level</i>	缺省情况下，本地用户的级别为0级。
配置本地用户所属的组	local- user <i>user-name</i> user-group <i>group-name</i>	缺省情况下，本地用户不属于任何用户组。
配置本地帐号的接入时间段	local-user <i>user-name</i> time-range <i>time-name</i>	缺省情况下，未配置本地帐号的接入时间段，即任意时间都允许接入。
配置指定用户的闲置切断时间	local-user <i>user-name</i> idle-timeout <i>minutes</i> [<i>seconds</i>] 或者 local-user <i>user-name</i> idle-cut	指定用户界面的超时时间。本地用户闲置时间超过设定时间，则用户自动下线。 设置用户连接的超时时间为0或者过长会导致终端一直处于登录状态，存在安全风险，建议用户执行命令lock锁定当前连接。 如果对普通用户（NAC或PPP用户等）进行闲置切断，则执行命令local-user <i>user-name</i> idle-cut进行配置，如果需要对管理用户进行闲置切断，请执行命令local-user <i>user-name</i> idle-timeout <i>minutes</i> [<i>seconds</i>]进行配置。
配置指定用户可建立的连接数目	local-user <i>user-name</i> access-limit <i>max-number</i>	缺省情况下，不限制用户可建立的连接数目。 如果需要设置本地帐号只能在唯一终端登录，可通过设置<i>max-number</i>的值为1实现该功能。

步骤5 （可选）配置本地用户安全性。

步骤		命令	说明
使能本地帐号锁定功能并配置用户的重试时间间隔、连续认证失败的限制次数及帐号锁定时间		local-aaa-user wrong-password retry-interval <i>retry-interval</i> retry-time <i>retry-time</i> block-time <i>block-time</i>	缺省情况下，本地帐号锁定功能处于使能状态，用户的重试时间间隔为5分钟、连续输入错误密码的限制次数为3次，帐号锁定时间为5分钟。
配置在用户帐号锁定期间，允许该用户使用指定的IP地址访问网络		aaa-quiet administrator except-list { <i>ipv4-address</i> <i>ipv6-address</i> } &<1-32>	缺省情况下，用户在帐号锁定期间不能访问网络。 通过命令 display aaa-quiet administrator except-list ，可以查询以上配置的IP地址信息。
配置本地接入用户密码策略	使能本地接入用户的密码策略功能并进入本地接入用户密码策略视图。	local-aaa-user password policy access-user	缺省情况下，本地接入用户的密码策略功能处于使能状态。
	配置每个用户密码的历史记录的最大条数。	password history record number <i>number</i>	缺省情况下，每个用户密码的历史记录的最大条数是5条。
	退出本地接入用户密码策略视图。	quit	-
配置本地管理员密码策略	使能本地管理员的密码策略功能并进入本地管理员密码策略视图。	local-aaa-user password policy administrator	缺省情况下，本地管理员的密码策略功能处于已使能状态。

步骤		命令	说明
	使能密码过期提醒功能并配置密码过期前的提醒时间。	password alert before-expire <i>day</i>	缺省情况下，密码过期前的提醒时间为30天。
	使能初始密码提醒功能。	password alert original	缺省情况下，初始密码修改提醒功能处于使能状态。
	使能密码过期功能并配置密码过期时间。	password expire <i>day</i>	缺省情况下，密码过期时间为90天。
	配置每个用户密码的历史记录的最大条数。	password history record number <i>number</i>	缺省情况下，每个用户密码的历史记录的最大条数是5条。
	退出本地管理员密码策略视图。	quit	-

步骤6 （可选）本地用户访问权限相关配置。

步骤	命令	说明
配置允许FTP用户访问的FTP目录	local-user <i>user-name</i> ftp-directory <i>directory</i>	缺省情况下，允许FTP用户访问的FTP目录为空。 若配置本地用户的接入类型为FTP方式，则必须配置本地用户的FTP目录，且本地用户的级别不能低于管理级，否则FTP用户无法登录。

步骤	命令	说明
配置本地用户的状态	local-user <i>user-name</i> state { active block }	缺省情况下，本地用户的状态为激活态。 设备对处于激活态和阻塞态用户的处理方式如下： - 若用户状态为激活态，将接收该用户的认证请求并做进一步处理。 - 若用户状态为阻塞态，将拒绝该用户的认证请求。
配置本地帐号的有效期	local-user <i>user-name</i> expire-date <i>expire-date</i>	缺省情况下，本地帐号永久有效。
配置本地用户的帐户类型	local-user <i>user-name</i> account-type cmcc-tr069	缺省情况下，未配置本地用户的帐户类型。 如果未通过命令 set operator-code cmcc 开启设备的TR-069功能，则本命令无法执行。

步骤7 执行命令**undo local-user password change-offline enable**，在本地管理员用户修改密码时，去使能与用户进行交互确认的功能。

缺省情况下，本地管理员用户在AAA视图下通过命令**local-user *user-name* password**修改密码时，已使能与用户进行交互确认的功能，设备会提示用户帐号将被注销，需要重新登录。

 说明

V300R021C10及之后版本支持此功能。

步骤8 （可选）修改本地用户登录密码。

步骤	命令	说明
返回用户视图	return	-
修改本地用户登录密码	local-user change-password	-

----结束

后续处理

视频：[配置AAA用户](#)

1.7.1.2 配置授权规则

背景信息

配置本地授权时，本地可配置的授权参数如表1-33所示：

表 1-33 本地授权参数

授权参数	应用场景	说明
VLAN	部署简单，维护成本也较低，由于其控制粒度在VLAN层面，适用于在同一办公室或同一部门所有人员权限相同的场景。	本地授权时，仅需在设备上配置VLAN及VLAN内的网络资源。 不支持为在线Portal用户授权VLAN。 用户获取VLAN授权后，需要手动触发DHCP申请IP地址。
业务方案	业务方案及业务方案所包括的网络资源需要在设备上配置。	设备上需要配置业务方案及业务方案内的网络资源。 业务方案可以被域引用，域下的用户就能获取业务方案的授权信息。
用户组	用户组指具有相同角色、相同权限等属性的一组用户（终端）的集合。例如，园区网中可以根据企业部门结构划分研发组、财务组、市场组、访客组等部门用户组，对于不同部门可授予不同安全策略。	本地授权时，仅需在设备上配置用户组及用户组内的网络资源。 用户组可以被域引用，域下的用户就能获取用户组的授权信息。 用户组的配置过程参见步骤 配置授权用户组 。

操作步骤

- 配置授权VLAN。
在设备上配置VLAN及VLAN内的网络资源。
- 配置授权业务方案。
具体配置请参见[1.7.3 配置业务方案](#)。
- 配置授权用户组。

步骤	命令	说明
创建用户组并进入用户组视图	user-group <i>group-name</i>	双机热备份场景或双链路备份场景下使用用户组时，必须指定用户组索引，并且主备设备上配置的用户组名和用户组索引必须一致。

步骤	命令	说明
在用户组下绑定ACL	acl-id <i>acl-number</i>	缺省情况下，用户组下未绑定ACL。 如果在用户组下绑定适用于IPv4用户的ACL，则必须使用命令 acl （系统视图）创建了ACL。
配置用户组优先级	remark { 8021p <i>8021p-value</i> dscp <i>dscp-value</i> exp <i>exp-value</i> lp <i>lp-value</i> }*	缺省情况下，未配置用户组优先级。

----结束

1.7.2 配置 AAA 方案

背景信息

如果需要采用本地方式进行认证和授权，需要在认证方案中配置认证模式为本地认证，在授权方案中配置授权模式为本地授权。

缺省情况下，设备对用户进行本地认证和授权。

说明

如果使用**authentication-mode**命令配置认证方式不为认证，则当用户上线时，用户输入任意的用户名和密码后都会认证成功。因此，为保护设备或网络安全，建议开启认证方式，保证用户经过认证后才可以访问设备或网络。

操作步骤

- 配置认证方案
 - 执行命令**system-view**，进入系统视图。
 - 执行命令**aaa**，进入AAA视图。
 - 执行命令**authentication-scheme** *authentication-scheme-name*，创建一个认证方案，并进入认证方案视图或直接进入一个已存在的认证方案视图。

缺省情况下，设备中有两个认证方案，认证方案名称分别是default和radius，default和radius方案均不能删除，只能修改方案下的参数。
 - 执行命令**authentication-mode** **local** | **local-case** }，配置认证模式为本地认证。

缺省情况下，认证模式为本地认证。
 - （可选）执行命令**authentication-super** [**hwtaacs** | **super**] * **none**，在当前认证模板下，配置对用户提升级别进行认证时采用的认证模式。

缺省情况下，用户提升级别时认证模式为**super**，即本地认证模式。
 - 执行命令**quit**，返回AAA视图。
 - （可选）执行命令**domainname-parse-direction** { **left-to-right** | **right-to-left** }，配置域名解析的方向，从左向右或从右向左。

缺省情况下，域名解析方向为从左向右。

- h. 执行命令**quit**，返回系统视图。
 - i. （可选）执行命令**aaa-authen-bypass enable time *time-value***，配置认证旁路时间。
缺省情况下，未启用旁路认证功能。
- 配置授权方案
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**aaa**，进入AAA视图。
 - c. 执行命令**authorization-scheme *authorization-scheme-name***，创建授权方案，并进入授权方案视图或直接进入一个已存在的授权方案视图。
缺省情况下，设备有一个授权方案，授权方案配置名是default，不能删除，只能修改。
 - d. 执行命令**authorization-mode local | local-case } [none]**，配置授权模式。
缺省情况下，授权模式为本地授权模式。
 - e. 执行命令**quit**，返回AAA视图。
 - f. （可选）执行命令**authorization-modify mode { modify | overlay }**，配置授权服务器下发的用户授权信息的生效模式。
缺省情况下，授权服务器下发的用户授权信息的生效模式为**overlay**模式。
 - g. 执行命令**quit**，返回系统视图。
 - h. （可选）执行命令**aaa-author-bypass enable time *time-value***，配置授权旁路时间。
缺省情况下，未启用旁路授权功能。

----结束

1.7.3 配置业务方案

背景信息

用户需要获取授权信息才能上线，可以通过配置业务方案管理用户的授权信息。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**aaa**，进入AAA视图。
- 步骤3** 执行命令**service-scheme *service-scheme-name***，创建一个业务方案并进入业务方案视图。
缺省情况下，设备中没有创建业务方案。
- 步骤4** 执行命令**admin-user privilege level *level***，配置用户可以作为管理员登录设备，同时指定登录时的管理员级别。
*level*参数的取值范围是0～15。缺省情况下，未配置用户级别。
- 步骤5** 配置相关服务器信息。

步骤	命令	说明
配置DHCP服务器组	dhcp-server group <i>group-name</i>	缺省情况下，业务方案下没有配置DHCP服务器组。
配置DNS主用服务器地址	dns <i>ip-address</i>	缺省情况下，业务方案下没有配置DNS主用服务器。
配置DNS备用服务器地址	dns <i>ip-address</i> secondary	缺省情况下，业务方案下没有配置DNS备用服务器。

步骤6 配置Efficient VPN场景下，Server端推送的资源。

步骤	命令	说明
配置wins主用服务器	wins <i>ip-address</i>	缺省情况下，业务方案下没有配置wins主用服务器。
配置wins备用服务器	wins <i>ip-address</i> secondary	缺省情况下，业务方案下没有配置wins备用服务器。
配置业务方案下的URL路径及版本号	auto-update url <i>url-string</i> version <i>version-number</i>	缺省情况下，业务方案下没有配置URL路径及版本号。
配置业务方案下的DNS缺省域名	dns-name <i>domain-name</i>	缺省情况下，业务方案下没有配置DNS缺省域名。
配置推送给对端的本端子网信息	route set acl <i>acl-number</i>	缺省情况下，未配置推送给对端的本端子网信息。
配置推送给对端的绑定IPSec的接口IP地址	route set interface	缺省情况下，未配置推送给对端的绑定IPSec的接口IP地址。

步骤7 执行命令**ip-pool** *pool-name* [**move-to** *new-position*]，配置业务方案下的IP地址池或者移动已配置的地址池的位置。

缺省情况下，业务方案下没有配置IP地址池。

 说明

配置前请确保IP地址池已经配置。

步骤8 执行命令**qos-profile profile-name**，绑定QoS模板。

缺省情况下，业务方案中没有绑定QoS模板。

 说明

配置前请确保QoS模板已经配置。

步骤9 执行命令**idle-cut idle-time flow-value [inbound | outbound]**，使能域用户的闲置切断功能并配置对应的闲置切断参数。

缺省情况下，域用户的闲置切断功能处于未使能状态。

 说明

闲置切断时间和闲置切断流量阈值是闲置切断功能生效的两个必要条件。其中，闲置切断流量阈值只能通过命令**idle-cut idle-time flow-value**配置；闲置切断时间可以使用设备上配置的数值（即参数**idle-time**）也可以使用RADIUS服务器授权的数值（由第28号RADIUS属性Idle-Timeout携带），两者同时存在时，RADIUS服务器授权的优先级高。

业务方案视图下的命令**idle-cut**，仅PPPoE用户和Portal用户生效。

----结束

1.7.4 在域下应用 AAA 方案

背景信息

创建的认证和授权方案，只有在域下应用后才能生效。采用本地方式进行认证和授权时，采用缺省的计费方案，即不计费。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**aaa**，进入AAA视图。

步骤3 执行命令**domain domain-name [domain-index domain-index]**，创建域并进入域视图或进入一个已存在的域视图。

缺省情况下，设备存在两个域：“default”和“default_admin”。“default”用于普通接入用户的域，“default_admin”用于管理员的域。

 说明

- 用户认证时，如果输入不带域名的用户名，将到默认域认证，因此设备需通过**domain domain-name [admin]**命令设置domain-name为全局默认域。
- 用户认证时，如果输入带域名的用户名，需要带上正确的域名domain-name。

步骤4 配置域的AAA方案：

步骤	命令	说明
配置域的认证方案	authentication-scheme authentication-scheme-name	缺省情况下，“default”域使用名为“radius”的认证方案，“default_admin”域使用名为“default”的认证方案，其他域使用名为“radius”的认证方案。

步骤	命令	说明
配置域的授权方案	authorization-scheme <i>authorization-scheme-name</i>	缺省情况下，域下没有绑定授权方案。

步骤5 （可选）配置本地授权规则：

步骤	命令	说明
（可选）配置对域下的用户下发用户组授权。	user-group <i>group-name</i>	缺省情况下，未配置对域下的用户下发用户组授权。
（可选）配置域的业务方案	service-scheme <i>service-scheme-name</i>	缺省情况下，域下没有配置任何业务方案。

步骤6 （可选）配置域的状态和流量统计功能：

步骤	命令	说明
配置域的状态	state { active block [time-range <i>time-name</i> <1-4>] }	当域处于阻塞状态时，属于该域的用户不能登录。缺省情况下，域创建后处于激活状态。

步骤7 （可选）执行命令**statistic enable**，使能域用户的流量统计功能。

缺省情况下，域用户的流量统计功能处于未使能状态。

步骤8 （可选）配置域名解析方案（如果在AAA视图和认证模板视图下都配置了域名解析，则优先使用认证模板上的配置。认证模板下的配置仅适用于无线用户）：

步骤	命令	说明
AAA视图	退出域视图 quit	-
	配置域名解析的方向 domainname-parse-direction { left-to-right right-to-left }	域名解析的方向可以是从左到右，或者从右到左。 缺省情况下，域名解析方向为从左到右。
	配置域名分隔符 domain-name-delimiter <i>delimiter</i>	域名分隔符可以是 \ / : < > @ ' % 中的某一个。 缺省情况下，域名分隔符为@。
	配置域名的位置 domain-location { after-delimiter before-delimiter }	缺省情况下，域名在分隔符后。

步骤		命令	说明
	配置安全字符串分隔符	security-name-delimiter <i>delimiter</i>	缺省情况下，安全字符串分隔符为*。

----结束

1.7.5 检查 AAA 的配置结果

操作步骤

- 执行命令**display aaa configuration**，查看AAA的概要信息。
- 执行命令**display authentication-scheme** [*authentication-scheme-name*]，查看认证方案的配置信息。
- 执行命令**display authorization-scheme** [*authorization-scheme-name*]，查看授权方案的配置信息。
- 执行命令**display access-user** [**domain** *domain-name* | **interface** *interface-type interface-number* [**vlan** *vlan-id* [**qinq** *qinq-vlan-id*]] | **ip-address** *ip-address* [**vpn-instance** *vpn-instance-name*] | **ipv6-address** *ipv6-address* | **access-slot** *slot-id* | **user-group** *user-group-name* | **username** *user-name*] [**detail**]、**display access-user** [**mac-address** *mac-address* | **service-scheme** *service-scheme-name* | **user-id** *user-id* | **statistics** | **ssid** *ssid-name*]或**display access-user access-type** { **admin** [**ftp** | **ssh** | **telnet** | **terminal** | **web**] | **ppp** | **l2tp** } [**username** *user-name*]，按照指定标准查看在线用户的概要信息。
- 执行命令**display domain** [**name** *domain-name*]，查看域的配置信息。
- 执行命令**display local-user** [**domain** *domain-name* | **state** { **active** | **block** } | **username** *username*] *，查看本地用户的属性信息。
- 执行命令**display local-user expire-time**，查看本地用户的过期时间。
- 执行命令**display aaa statistics access-type-authenreq**，查看认证请求数。

----结束

1.8 配置采用 RADIUS 方式进行认证、授权和计费

RADIUS 方式进行认证、授权和计费

RADIUS（Remote Authentication Dial-In User Service）是一种客户端/服务器结构的信息交互协议，能保护网络不受未授权访问的干扰，常应用在既要求较高安全性、又允许远程用户访问的各种网络环境中。

配置流程

1.8.1 配置 AAA 方案

背景信息

用户使用的认证、授权和计费方法通过AAA方案来定义。如果使用RADIUS方式进行认证、授权和计费，需要在认证方案中配置认证模式为RADIUS认证，在计费方案中配置计费模式为RADIUS计费。RADIUS认证与授权结合，不能分离，认证成功授权也成功。所以不需要配置授权方案，仅需配置认证方案和计费方案。

为避免单一认证模式无响应而造成的认证失败，一般会在认证方案中配置本地认证或不认证为备份认证模式。

说明

如果使用**authentication-mode**命令配置认证方式不为认证，则当用户上线时，用户输入任意的用户名和密码后都会认证成功。因此，为保护设备或网络安全，建议开启认证方式，保证用户经过认证后才可以访问设备或网络。

操作步骤

- 配置认证方案

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**aaa**，进入AAA视图。
- c. 执行命令**authentication-scheme *scheme-name***，创建一个认证方案并进入认证方案视图，或者直接进入一个已经存在的认证方案视图。

缺省情况下，设备中有两个认证方案，认证方案名称分别是default和radius，default和radius方案均不能删除，只能修改方案下的参数。

- d. 执行命令**authentication-mode radius**，配置认证模式为RADIUS认证。

缺省情况下，认证模式为本地认证。

如果需要配置本地认证为备份认证模式，请执行命令**authentication-mode radius local | local-case** }。

- e. （可选）执行命令**undo server no-response accounting**，配置用户在服务器认证无响应转入本地认证后，设备不发送计费报文。

缺省情况下，在配置了服务器计费的情况下，用户在服务器认证无响应转入本地认证后，设备不发送计费报文。

- f. （可选）执行命令**radius-reject local**，配置管理员用户在RADIUS认证拒绝后转入本地认证。

缺省情况下，未配置管理员用户在RADIUS认证拒绝后转入本地认证。在RADIUS认证拒绝后（即RADIUS服务器回应Access-Reject报文），认证流程结束，用户认证失败。

说明

- 该功能仅对管理员用户生效。
 - 实现该功能认证模式必须为RADIUS+本地认证。
- g. 执行命令**quit**，返回AAA视图。

- h. （可选）配置帐号锁定功能
 - i. 执行命令**access-user remote authen-fail retry-interval *retry-interval* retry-time *retry-time* block-time *block-time***，开启接入用户远端认证失败后帐号锁定功能。
或者：执行命令**administrator remote authen-fail retry-interval *retry-interval* retry-time *retry-time* block-time *block-time***，开启管理员用户远端认证失败后帐号锁定功能。
缺省情况下，接入用户远端认证失败后帐号锁定功能处于关闭状态；管理员用户远端认证失败后帐号锁定功能处于开启状态，并且，远端认证失败后用户的重试时间间隔为5分钟，连续认证失败的限制次数为30次，帐号锁定时间为5分钟。
 - ii. 执行命令**aaa-quiet administrator except-list { *ipv4-address* | *ipv6-address* } <1-32>**，配置在用户帐号锁定期间，允许该用户使用指定的IP地址访问网络。
缺省情况下，用户在帐号锁定期间不能访问网络。
通过命令**display aaa-quiet administrator except-list**，可以查询以上配置的IP地址信息。
 - iii. 执行命令**remote-user authen-fail unblock { all | *username username* }**，将认证失败的远端认证帐号解锁。
 - i. （可选）执行命令**aaa-author session-timeout invalid-value enable**，配置当RADIUS服务器下发的Session-Timeout为0时，设备不对用户进行下线或重认证。
缺省情况下，当Radius服务器下发的Session-Timeout属性值为0时，该属性不生效。
 - j. 执行命令**quit**，返回系统视图。
 - k. （可选）执行命令**aaa-authen-bypass enable time *time-value***，配置认证旁路时间。
缺省情况下，未启用旁路认证功能。
- 配置计费方案
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**aaa**，进入AAA视图。
 - c. 执行命令**accounting-scheme *accounting-scheme-name***，创建一个计费方案，并进入计费方案视图或直接进入一个已存在的计费方案视图。
缺省情况下，设备中有一个计费方案，计费方案配置名是default，default方案不能删除，只能修改default方案下的参数。
 - d. 执行命令**accounting-mode radius**，配置计费模式为RADIUS计费。
缺省情况下，不计费，即计费模式为none。
 - e. （可选）配置计费失败策略
 - 开始计费失败策略
执行命令**accounting start-fail { offline | online }**，配置开始计费失败策略。
缺省情况下，如果开始计费失败，不允许用户上线。
 - 实时计费失败策略

- 1) 执行命令**accounting realtime interval**，使能实时计费并设置计费间隔。

缺省情况下，设备按时长计费，未使能实时计费功能。

- 2) 执行命令**accounting interim-fail [max-times times] { offline | online }**，配置允许的实时计费请求最大无响应次数，以及实时计费失败后采取的策略。

缺省情况下，允许的实时计费请求最大无响应次数为3次，实时计费失败后允许用户在线。

■ 结束计费失败策略

- 1) 执行命令**quit**，返回AAA视图。
- 2) 执行命令**quit**，返回系统视图。
- 3) 执行命令**radius-server template template-name**，进入RADIUS服务器模板视图。
- 4) 执行命令**radius-server accounting-stop-packet resend [resend-times]**，配置计费结束报文的重传功能以及可重发的计费结束报文个数。

缺省情况下，允许重发计费结束报文，且计费结束报文的重发次数为3。

- f. （可选）执行命令**quit**，返回系统视图。
- g. （可选）执行命令**authentication-profile name authentication-profile-name**，进入认证模板视图。

缺省情况下，设备自带6个认证模板，名称分别为default_authen_profile、dot1x_authen_profile、mac_authen_profile、portal_authen_profile、dot1xmac_authen_profile和multi_authen_profile。

----结束

检查配置结果

- 执行命令**display authentication-scheme [authentication-scheme-name]**，查看认证方案的配置信息。
- 执行命令**display accounting-scheme [accounting-scheme-name]**，查看计费方案的配置信息。

1.8.2 配置 RADIUS 服务器模板

背景信息

设备通过RADIUS服务器模板来指定与其对接的RADIUS服务器，RADIUS服务器模板内包含服务器的IP地址、端口号、源接口、共享密钥等配置。

RADIUS服务器模板下的配置要与RADIUS服务器上的配置一致。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**radius-server template template-name**，进入RADIUS服务器模板视图。

缺省情况下，设备上存在一个名为“default”的RADIUS服务器模板，只能修改，不能删除。

步骤3 配置RADIUS认证、计费服务器：

配置	命令	说明
配置RADIUS认证服务器	- 配置IPv4服务器：radius-server authentication <i>ipv4-address</i> <i>port</i> [vpn-instance <i>vpn-instance-name</i> source { loopback <i>interface-number</i> ip-address <i>ipv4-address</i> vlanif <i>interface-number</i> } weight <i>weight-value</i>] * - 配置IPv6服务器：radius-server authentication <i>ipv6-address</i> <i>port</i> [source { loopback <i>interface-number</i> ip-address <i>ipv6-address</i> vlanif <i>interface-number</i> } weight <i>weight-value</i>] *	缺省情况下，未配置RADIUS认证服务器。
配置RADIUS计费服务器	- 配置IPv4服务器：radius-server accounting <i>ipv4-address</i> <i>port</i> [vpn-instance <i>vpn-instance-name</i> source { loopback <i>interface-number</i> ip-address <i>ipv4-address</i> vlanif <i>interface-number</i> } weight <i>weight-value</i>] * - 配置IPv6服务器：radius-server accounting <i>ipv6-address</i> <i>port</i> [source { loopback <i>interface-number</i> ip-address <i>ipv6-address</i> vlanif <i>interface-number</i> } weight <i>weight-value</i>] *	缺省情况下，未配置RADIUS计费服务器。

步骤4 执行命令**radius-server shared-key cipher** *key-string*，配置RADIUS服务器的共享密钥。

您可以在《AR路由器 缺省帐号与密码》（[企业网](#)、[运营商](#)）文档中获取各种缺省帐号与密码信息。获取该文档需要权限，如需升级权限，请查看网站帮助。

 说明

同一个RADIUS服务器同时配置在多个RADIUS服务器模板下时：

- 如果不同RADIUS服务器模板下的共享密钥不同，则需要在每个RADIUS服务器模板视图下分别配置。
- 如果所有RADIUS服务器模板下的共享密钥相同，则可以在系统视图下配置。配置命令为**radius-server ip-address** { *ipv4-address* | *ipv6-address* } **shared-key cipher** *key-string*。
- RADIUS服务器模板视图下和系统视图下都配置RADIUS服务器的密钥时，系统视图下配置的RADIUS服务器密钥优先生效。

步骤5 （可选）执行命令**radius-server algorithm** { **loading-share** | **master-backup** } [**based-user**]，配置RADIUS服务器的运算法则。

缺省情况下，RADIUS服务器采用基于单个用户的主备运算法则。

当RADIUS服务器模板下配置多台认证或者计费服务器时，设备根据配置的运算法则和权重参数**weight**，决定如何选择RADIUS服务器：

- 若选择主备算法，则权重参数**weight**决定主备，**weight**值较大者为主，如果**weight**值相同，则先配置的服务器为主服务器。
- 如选择负载均衡算法，则权重参数**weight**决定报文的分配。

步骤6 （可选）执行命令**radius-server { retransmit *retry-times* | timeout *time-value* }** *，RADIUS请求报文的超时重传次数和超时时间。

缺省情况下，RADIUS认证请求报文的超时重传次数为3，超时时间是5秒。

步骤7 （可选）配置设备向RADIUS服务器发送的报文中的用户名的格式。

- 执行命令**radius-server user-name domain-included**，配置设备向RADIUS服务器发送的报文中的用户名包含域名。
- 执行命令**radius-server user-name original**，配置设备向RADIUS服务器发送的报文中的用户名为用户原始输入的用户名，设备不对其进行修改。
- 执行命令**undo radius-server user-name domain-included**，配置设备向RADIUS服务器发送的报文中的用户名不包含域名。
- 执行命令**undo radius-server user-name domain-included except-eap**，配置除EAP认证外的其他认证方式，设备向RADIUS服务器发送的报文中的用户名不包含域名。

缺省情况下，设备向RADIUS服务器发送的报文中的用户名为用户原始输入的用户名，设备不对其进行修改。

步骤8 （可选）执行命令**radius-server traffic-unit { byte | kbyte | mbyte | gbyte }**，配置RADIUS服务器的流量单位。

缺省情况下，设备以（byte）作为RADIUS流量单位。

步骤9 （可选）执行命令**radius-attribute service-type with-authenonly-reauthen**，配置重认证方式为只重认证不重授权。

缺省情况下，重认证方式为重认证和重授权。

当RADIUS服务器的Service-Type属性为Authenticate Only时，该功能才可以生效。

步骤10 （可选）执行命令**radius-server framed-ip-address no-user-ip enable**，当用户发送的RADIUS认证请求报文中没有携带用户IP地址时，使能设备在RADIUS认证请求报文中封装RADIUS属性Framed-IP-Address的功能。

缺省情况下，当用户发送的RADIUS认证请求报文中没有携带用户IP地址时，未使能设备在RADIUS认证请求报文中封装RADIUS属性Framed-IP-Address的功能。

----结束

检查配置结果

执行命令**display radius-server configuration [template *template-name*]**，查看RADIUS服务器模板的配置信息。

测试 RADIUS 服务器的连通性

执行命令 **test-aaa user-name user-password radius-template template-name [chap | pap | accounting [start | realtime | stop]]**，测试设备与认证服务器或计费服务器的连通性，认证服务器或计费服务器是否可以正常对用户进行认证或计费。

常见的故障返回信息及对应的处理手段请参见[测试单个用户能否通过RADIUS认证或计费](#)。

1.8.3 （可选）配置 RADIUS 服务器状态探测功能

背景信息

设备通过RADIUS服务器状态探测功能感知RADIUS服务器的状态，在RADIUS服务器状态为Down时，使用户能够获取逃生权限；在RADIUS服务器状态恢复Up后，用户退出逃生权限，进行重认证。

操作步骤

- 配置将RADIUS服务器的状态标记为Down的条件，分为两种
 - 在RADIUS服务器状态探测过程中，将RADIUS服务器标记为Down状态的条件。
 - i. 执行命令**system-view**，进入系统视图。
 - ii. 执行命令**radius-server { dead-interval dead-interval | dead-count dead-count | detect-cycle detect-cycle }**，配置RADIUS服务器的探测周期、每个探测周期连续无响应的最大次数和探测周期循环次数。
 - iii. 执行命令**return**，返回到用户视图。
 - 将长时间无响应的RADIUS服务器标记为Down状态。该功能一直开启，通过以下配置可以调节RADIUS服务器无响应的最大时间间隔。
 - i. 执行命令**system-view**，进入系统视图。
 - ii. 执行命令**radius-server max-unresponsive-interval interval**，配置RADIUS服务器无响应的最大时间间隔。
缺省情况下，RADIUS服务器无响应的最大时间间隔是300秒。
 - iii. 执行命令**return**，返回到用户视图。
- （可选）配置自动探测功能
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**radius-server template template-name**，进入RADIUS服务器模板视图。
 - c. 执行命令**radius-server testuser username user-name password cipher password**，创建RADIUS自动探测用户。
缺省情况下，系统没有配置基于RADIUS模板的自动探测用户。
RADIUS自动探测用户创建完成后，自动探测功能开启。自动探测功能默认仅对Down状态的RADIUS服务器进行探测。
 - d. （可选）执行命令**radius-server detect-server interval interval**，配置对Down状态的RADIUS服务器的自动探测周期。
缺省情况下，对Down状态的RADIUS服务器的自动探测周期为60秒。

- e. （可选）执行命令**radius-server detect-server up-server interval interval**，开启对Up状态的RADIUS服务器的自动探测功能并配置自动探测周期。

缺省情况下，设备不对Up状态的RADIUS服务器进行自动探测。

说明

在大型企业网络中，不建议开启对Up状态的RADIUS服务器进行自动探测的功能。这是由于如果多个NAS设备均开启该功能，RADIUS服务器在处理用户认证请求报文的同时还会收到大量周期性的探测报文，会降低RADIUS服务器的处理性能。

配置自动探测功能（命令**radius-server testuser**）后，**dead-time**定时器（命令**radius-server dead-time**）不生效。

- f. （可选）执行命令**radius-server detect-server timeout timeout**，配置RADIUS探测报文的超时等待时间。

缺省情况下，RADIUS探测报文的超时等待时间为3秒。

- g. 执行命令**return**，返回到用户视图。

- （可选）配置RADIUS服务器Down状态可持续的时长，即配置强制Up定时器

说明

在开启自动探测功能的情况下，RADIUS服务器的状态被标记为Force-up后，设备会立即发送探测报文，在超时等待时间内，如果收到RADIUS服务器的报文，设备会将RADIUS服务器的状态标记为Up；反之，则将RADIUS服务器的状态标记为Down。

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**radius-server template template-name**，进入RADIUS服务器模板视图。
- c. 执行命令**radius-server dead-time dead-time**，配置RADIUS服务器强制Up定时器。

缺省情况下，RADIUS服务器强制Up定时器时长为5分钟。

- d. 执行命令**return**，返回到用户视图。

- （可选）配置RADIUS认证服务器和计费服务器的状态同步

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**radius-server dead-detect-condition by-server-ip**，配置基于IP地址对RADIUS服务器进行自动探测。

缺省情况下，相同VPN实例下，相同IP地址的RADIUS认证服务器和计费服务器同步探测，状态同步更新。

- c. 执行命令**return**，返回到用户视图。

----结束

检查配置结果

- 执行命令**display radius-server { dead-interval | dead-count | detect-cycle }**，查看RADIUS服务器的探测周期、每个探测周期连续无响应的最大次数和探测周期循环次数的配置信息。
- 执行命令**display radius-server configuration**，查看RADIUS服务器模板下自动探测用户、探测周期以及探测报文超时等待时间的配置信息。
- 执行命令**display radius-server max-unresponsive-interval**，查看RADIUS服务器无响应的最大时间间隔的配置信息。

后续处理

1. 在认证模板视图下，执行命令**authentication event authen-server-down action authorize**，配置在认证服务器Down时的逃生功能。具体配置请参见NAC配置中的[3.5.3.3（可选）配置认证事件授权信息](#)。
2. 在认证模板视图下，执行命令**authentication event authen-server-up action re-authen**，配置认证服务器恢复为Up后的重认证功能。具体配置请参见NAC配置中的[3.5.3.5（可选）配置对用户进行重认证](#)。

1.8.4（可选）配置 RADIUS 属性

1.8.4.1 配置 RADIUS 属性禁用和转换功能

背景信息

由于不同厂商支持的RADIUS属性存在不兼容问题，因此在对接替换场景中经常使用RADIUS属性禁用功能和RADIUS属性转换功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**radius-server template *template-name***，进入RADIUS服务器模板视图。

缺省情况下，设备上存在一个名为“default”的RADIUS服务器模板，只能修改，不能删除。

步骤3 执行命令**radius-server attribute translate**，启动RADIUS属性禁用和转换功能。

缺省情况下，未启动RADIUS属性禁用和转换功能。

步骤4 执行命令**radius-attribute disable *attribute-name* { receive | send } ***，配置RADIUS属性禁用功能。

缺省情况下，所有RADIUS属性均未被禁用。

步骤5 配置RADIUS属性转换功能。

- **radius-attribute translate *src-attribute-name* *dest-attribute-name* { receive | send | access-accept | access-request | account-request | account-response } ***
- **radius-attribute translate extend vendor-specific *src-vendor-id* *src-sub-id* *dest-attribute-name* { access-accept | account-response } ***
- **radius-attribute translate extend *src-attribute-name* vendor-specific *dest-vendor-id* *dest-sub-id* { access-request | account-request } ***

缺省情况下，没有转换任何RADIUS属性。

----结束

检查配置结果

- 执行命令**display radius-attribute [name *attribute-name* | type { *attribute-number1* | huawei *attribute-number2* | microsoft *attribute-number3* }]**，查看设备支持的RADIUS属性。

- 执行命令**display radius-attribute [template *template-name*] disable**，查看设备禁用的RADIUS属性。
- 执行命令**display radius-attribute [template *template-name*] translate**，查看RADIUS属性转换的配置信息。

1.8.4.2 配置 RADIUS 属性检查功能

背景信息

配置RADIUS属性检查功能后，设备检查接收的RADIUS认证成功报文中是否携带指定属性，携带有该属性则按认证成功处理，未携带则按认证失败处理、丢弃该报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**radius-server template *template-name***，进入RADIUS服务器模板视图。

缺省情况下，设备上存在一个名为“default”的RADIUS服务器模板，只能修改，不能删除。

步骤3 执行命令**radius-attribute check *attribute-name***，配置对接收的RADIUS认证成功报文内的指定属性进行检查。

缺省情况下，对接收的RADIUS认证成功报文不做检查。

----结束

1.8.4.3 更改 RADIUS 属性值

背景信息

不同厂商的RADIUS服务器支持的同一属性的属性值可能有所不同。为了实现与不同的RADIUS服务器对接，设备支持更改RADIUS属性的值。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**radius-server template *template-name***，进入RADIUS服务器模板视图。

缺省情况下，设备上存在一个名为“default”的RADIUS服务器模板，只能修改，不能删除。

步骤3 执行命令**radius-attribute set *attribute-name attribute-value* [auth-type { mac | dot1x | portal } | user-type ipsession]**，更改RADIUS属性的属性值。

缺省情况下，RADIUS属性的属性值不会被修改。

说明

当RADIUS服务器发送的Access-challenge报文中EAP内容比较大（长度都超过1200），可能导致终端接收EAP Request challenge报文失败，可尝试通过该命令设置`attribute-name`为Framed-MTU来降低设备发送给RADIUS服务器认证请求报文中Framed-MTU属性值，其中Framed-MTU属性值默认为1500，可将其调整为1000。部分第三方RADIUS服务器不支持该属性，无法达到限制RADIUS服务器报文长度的效果。

----结束

1.8.4.4 配置 RADIUS 标准属性

背景信息

设备支持的RADIUS属性及其说明请参考[RADIUS属性](#)。部分RADIUS标准属性的内容或格式支持可配置。

操作步骤

步骤1 执行命令`system-view`，进入系统视图。

步骤2 执行命令`radius-server template template-name`，进入RADIUS服务器模板视图。

缺省情况下，设备上存在一个名为“default”的RADIUS服务器模板，只能修改，不能删除。

步骤3 配置RADIUS标准属性

- **配置RADIUS属性4（NAS-IP-Address）和RADIUS属性95（NAS-IPv6-Address）**
 - 执行命令`radius-attribute nas-ip { ip-address | ap-info }`，配置RADIUS属性4（NAS-IP-Address）。
缺省情况下，使用NAS的源IP地址作为NAS-IP-Address属性的值。
 - 执行命令`radius-attribute nas-ipv6 ipv6-address`，配置RADIUS属性95（NAS-IPv6-Address）。
缺省情况下，未配置NAS-IPv6-Address属性。
- **配置RADIUS属性5（NAS-Port）**
 - a. 执行命令`radius-server nas-port-format { new | old }`，配置NAS（Network Access Server）端口的形式。
缺省情况下，NAS端口形式采用新格式。
当NAS端口形式采用新格式时，可以执行以下步骤配置new格式的具体形式。
 - b. 执行命令`radius-server format-attribute nas-port nas-port-string [ decimal ]`，NAS端口形式采用new格式的具体形式。
缺省情况下，NAS端口形式采用新格式的默认形式。
- **配置RADIUS属性30（Called-Station-Id）**
 - a. 执行命令`called-station-id mac-format { dot-split | hyphen-split | colon-split } [ mode1 | mode2 ] [ lowercase | uppercase ]`或者`called-station-id mac-format unformatted [ lowercase | uppercase ]`，配置RADIUS属性30（Called-Station-Id）中MAC地址的封装格式。

缺省情况下，RADIUS属性30（Called-Station-Id）中MAC地址的格式为XX-XX-XX-XX-XX，大写形式。

- **配置RADIUS属性31（Calling-Station-Id）**

执行命令**calling-station-id mac-format { dot-split | hyphen-split | colon-split } [mode1 | mode2] [lowercase | uppercase]**或者**calling-station-id mac-format { unformatted [lowercase | uppercase] | bin }**，配置RADIUS属性31（Calling-Station-Id）中MAC地址的封装格式。

缺省情况下，RADIUS属性31（Calling-Station-Id）中MAC地址的封装格式为xxxx-xxxx-xxxx，小写形式。

- **配置RADIUS属性32（NAS-Identifier）**

执行命令**radius-server nas-identifier-format { hostname | vlan-id | ap-info }**，配置NAS-Identifier属性封装的形式。

缺省情况下，NAS-Identifier属性封装的形式为NAS设备的主机名。

- **配置RADIUS属性80（Message-Authenticator）**

执行命令**radius-server attribute message-authenticator access-request**，配置设备发送认证报文时，携带RADIUS属性80（Message-Authenticator）。

缺省情况下，认证报文未携带RADIUS属性80（Message-Authenticator）。

- **配置RADIUS属性87（NAS-Port-Id）**

执行命令**radius-server nas-port-id-format { new | old }**，配置NAS端口ID的形式。

缺省情况下，采用新的NAS端口ID形式。

- **配置RADIUS属性89（Chargeable-User-Identity）**

执行命令**radius-server support chargeable-user-identity [not-reject]**，配置设备支持CUI属性。

缺省情况下，设备不支持CUI属性。

----结束

1.8.4.5 配置华为 RADIUS 扩展属性

背景信息

设备支持的RADIUS属性及其说明请参考[RADIUS属性](#)。部分华为RADIUS扩展属性的内容或格式支持可配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**radius-server template template-name**，进入RADIUS服务器模板视图。

缺省情况下，设备上存在一个名为“default”的RADIUS服务器模板，只能修改，不能删除。

步骤3 配置华为RADIUS扩展属性

- 执行命令**radius-server hw-ap-info-format include-ap-ip**，配置华为RADIUS扩展属性26-141（HW-AP-Information）中携带AP设备的IP地址。

缺省情况下，华为RADIUS扩展属性26-141（HW-AP-Information）中不携带AP设备的IP地址。

- 执行命令**radius-attribute cut hw-portal-url key-words [end mark]**，配置在华为RADIUS属性26-156（HW-Portal-URL）携带的URL中删除指定的内容。
缺省情况下，设备不处理华为RADIUS属性26-156（HW-Portal-URL）携带的URL。

----结束

1.8.5 （可选）配置授权信息

1.8.5.1 配置业务方案

背景信息

用户需要获取授权信息才能上线，可以通过配置业务方案管理用户的授权信息。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**aaa**，进入AAA视图。
- 步骤3** 执行命令**service-scheme service-scheme-name**，创建一个业务方案并进入业务方案视图。
- 缺省情况下，设备中没有创建业务方案。
- 步骤4** 执行命令**admin-user privilege level level**，配置用户可以作为管理员登录设备，同时指定登录时的管理员级别。
- level*参数的取值范围是0～15。缺省情况下，未配置用户级别。
- 步骤5** 配置相关服务器信息。

步骤	命令	说明
配置DHCP服务器组	dhcp-server group group-name	缺省情况下，业务方案下没有配置DHCP服务器组。
配置DNS主用服务器地址	dns ip-address	缺省情况下，业务方案下没有配置DNS主用服务器。
配置DNS备用服务器地址	dns ip-address secondary	缺省情况下，业务方案下没有配置DNS备用服务器。

- 步骤6** 配置Efficient VPN场景下，Server端推送的资源。

步骤	命令	说明
配置wins主用服务器	wins ip-address	缺省情况下，业务方案下没有配置wins主用服务器。

步骤	命令	说明
配置wins备用服务器	wins <i>ip-address secondary</i>	缺省情况下，业务方案下没有配置wins备用服务器。
配置业务方案下的URL路径及版本号	auto-update url <i>url-string version version-number</i>	缺省情况下，业务方案下没有配置URL路径及版本号。
配置业务方案下的DNS缺省域名	dns-name <i>domain-name</i>	缺省情况下，业务方案下没有配置DNS缺省域名。
配置推送给对端的本端子网信息	route set acl <i>acl-number</i>	缺省情况下，未配置推送给对端的本端子网信息。
配置推送给对端的绑定IPSec的接口IP地址	route set interface	缺省情况下，未配置推送给对端的绑定IPSec的接口IP地址。

步骤7 执行命令**ip-pool** *pool-name* [**move-to** *new-position*]，配置业务方案下的IP地址池或者移动已配置的地址池的位置。

缺省情况下，业务方案下没有配置IP地址池。

 说明

配置前请确保IP地址池已经配置。

步骤8 执行命令**qos-profile** *profile-name*，绑定QoS模板。

缺省情况下，业务方案中没有绑定QoS模板。

 说明

配置前请确保QoS模板已经配置。

步骤9 执行命令**idle-cut** *idle-time flow-value* [**inbound** | **outbound**]，使能域用户的闲置切断功能并配置对应的闲置切断参数。

缺省情况下，域用户的闲置切断功能处于未使能状态。

 说明

闲置切断时间和闲置切断流量阈值是闲置切断功能生效的两个必要条件。其中，闲置切断流量阈值只能通过命令 **idle-cut idle-time flow-value** 配置；闲置切断时间可以使用设备上配置的数值（即参数 *idle-time*）也可以使用RADIUS服务器授权的数值（由第28号RADIUS属性Idle-Timeout携带），两者同时存在时，RADIUS服务器授权的优先级高。

业务方案视图下的命令 **idle-cut**，仅PPPoE用户和Portal用户生效。

----结束

1.8.5.2 配置用户组

背景信息

用户需要获取授权信息才能上线，可以通过配置用户组管理用户的授权信息。

操作步骤

- 配置用户组

步骤	命令	说明
创建用户组并进入用户组视图	user-group group-name	双机热备份场景或双链路备份场景下使用用户组时，必须指定用户组索引，并且主备设备上配置的用户组名和用户组索引必须一致。
在用户组下绑定ACL	acl-id acl-number	缺省情况下，用户组下未绑定ACL。 如果在用户组下绑定适用于IPv4用户的ACL，则必须使用命令 acl （系统视图）创建了ACL。
配置用户组优先级	remark { 8021p 8021p-value dscp dscp-value exp exp-value lp lp-value }*	缺省情况下，未配置用户组优先级。

----结束

1.8.6 创建域和配置域

背景信息

NAS设备对用户的管理是基于域的，每个用户都属于一个域，一个域是由属于同一个域的用户构成的群体。简单地说，用户属于哪个域就使用哪个域下的AAA配置信息。

设备根据用户名决定用户所属的域。对用户进行认证、授权和计费前，需要先创建用户所属的域。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**aaa**，进入AAA视图。

步骤3 执行命令**domain domain-name [domain-index domain-index]**，创建域并进入域视图或进入一个已存在的域视图。

缺省情况下，设备存在两个域：“default”和“default_admin”。“default”用于普通接入用户的域，“default_admin”用于管理员的域。

步骤4 （可选）执行命令**state { active | block [time-range time-name <1-4>] }**，配置域的状态。

缺省情况下，域创建后处于激活状态。当域处于阻塞状态时，属于该域的用户不能登录。

步骤5 （可选）执行命令**statistic enable**，使能域用户的流量统计功能。

缺省情况下，域用户的流量统计功能处于未使能状态。

步骤6 （可选）配置域名解析方案，对设备上所有域都有效

1. 执行命令**quit**，退回到AAA视图。

2. 执行命令**domainname-parse-direction { left-to-right | right-to-left }**，配置域名解析的方向。

缺省情况下，域名解析方向为从左向右。

3. 执行命令**domain-name-delimiter delimiter**，配置域名分隔符。

缺省情况下，域名分隔符为@。

4. 执行命令**domain-location { after-delimiter | before-delimiter }**，配置域名的位置。

缺省情况下，域名在分隔符后。

说明

认证模板下也支持配置域名方案，如果在AAA视图和认证模板视图下都配置了域名解析方案，则优先使用认证模板下的配置。认证模板下的配置仅适用于无线用户。

步骤7 （可选）配置安全字符串功能

1. 执行命令**security-name enable**，使能安全字符串功能。

缺省情况下，已使能安全字符串功能。

2. 执行命令**security-name-delimiter delimiter**，配置安全字符串分隔符。

缺省情况下，安全字符串分隔符为*。

说明

认证模板下也支持配置安全字符串，如果在AAA视图和认证模板视图下都配置了安全字符串，则优先使用认证模板下的配置。认证模板下的配置仅适用于无线用户。

步骤8 （可选）配置无线用户的允许域（此步骤仅适用于无线用户）：

步骤	命令	说明
退出到系统视图	quit	-

步骤	命令	说明
创建认证模板并进入认证模板视图	authentication-profile name <i>authentication-profile-name</i>	缺省情况下，设备自带6个认证模板，名称分别为 default_authen_profile、dot1x_authen_profile、mac_authen_profile、portal_authen_profile、dot1xmac_authen_profile和 multi_authen_profile。
配置无线用户的允许域	permit-domain name <i>domain-name</i> <1-4>	缺省情况下，没有配置无线用户的允许域。 用户在认证模板下面配置了用户允许域后，只有允许域内的用户才能通过认证、授权和计费。

----结束

1.8.7 配置全局默认域

背景信息

设备根据用户的用户名决定用户所属的域。当用户名中没有携带域名、设备无法确认用户所属的域时，将用户加入到全局默认域中。根据用户类型的不同（接入用户或者管理员用户），全局默认域又分为全局默认普通域和全局默认管理域。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置全局默认域

- 执行命令**domain domain-name**，配置全局默认普通域。
- 执行命令**domain domain-name admin**，配置全局默认管理域。

缺省情况下，全局默认域有两个：全局默认普通域“default”和全局默认管理域“default_admin”。

说明

全局默认普通域和全局默认管理域可以配置为同一个域。

----结束

查看当前配置的全局默认域

执行命令**display aaa configuration**，可以查看设备当前配置的全局默认域。

```
<Huawei> display aaa configuration
Domain Name Delimiter      : @
Domainname parse direction : Left to right
Domainname location        : After-delimiter
Administrator user default domain: default_admin //全局默认管理域
Normal user default domain  : default //全局默认普通域
```

1.8.8 在域下应用 AAA 方案、RADIUS 服务器模板和授权信息

背景信息

域统一管理AAA方案、服务器模板等配置信息，另外，域下还可以配置授权信息。用户属于哪个域就使用哪个域下的AAA配置信息。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**aaa**，进入AAA视图。

步骤3 执行命令**domain domain-name [domain-index domain-index]**，创建域并进入域视图或进入一个已存在的域视图。

缺省情况下，设备存在两个域：“default”和“default_admin”。“default”用于普通接入用户的域，“default_admin”用于管理员的域。

步骤4 执行命令**authentication-scheme scheme-name**，配置域下应用的认证方案。

缺省情况下，“default”域使用名为“radius”的认证方案，“default_admin”域使用名为“default”的认证方案，其他域使用名为“radius”的认证方案。

步骤5 执行命令**accounting-scheme accounting-scheme-name**，配置域下应用的计费方案。

缺省情况下，域使用名为“default”的计费方案。“default”计费方案的策略为：计费模式为不计费，关闭实时计费开关。

步骤6 执行命令**radius-server template-name**，配置域下应用的RADIUS服务器模板。

缺省情况下，“default”域下绑定了名为“default”的RADIUS服务器模板，“default_admin”域下没有绑定RADIUS服务器模板，其他域下绑定了名为“default”的RADIUS服务器模板。

步骤7 （可选）执行命令**accounting-copy radius-server template-name**，开启RADIUS计费报文抄送功能并配置二级计费RADIUS服务器模板。

缺省情况下，未开启RADIUS计费报文抄送功能。

说明

- 用户需保证配置的二级计费RADIUS服务器的IP地址与一级计费RADIUS服务器的IP地址不相同（包括主/备用RADIUS计费服务器）。
- 域下配置的二级计费RADIUS服务器模板与域下用于认证和计费的RADIUS服务器模板不能相同，相同则无法配置系统会报错。

步骤8 （可选）域下配置授权信息

- 执行命令**user-group group-name**，配置对域下的用户下发用户组授权。
缺省情况下，未配置对域下的用户下发用户组授权。

- 执行命令**service-scheme service-scheme-name**，配置对域下的用户下发业务方案授权。
缺省情况下，未配置对域下的用户下发业务方案授权。

----结束

检查配置结果

执行命令**display domain [name domain-name]**，查看域的配置信息。

1.8.9 配置 RADIUS CoA/DM 功能

背景信息

设备支持RADIUS CoA/DM功能，提供一种动态修改在线用户权限或者强制用户下线的机制。

 说明

如果MAC和Dot1x用户没有配置计费功能，在上线后发生AC间漫游，配置RADIUS CoA/DM功能将不生效。

操作步骤

- 步骤1 执行命令**system-view**，进入系统视图。
- 步骤2 执行命令**radius-server authorization server-source { ip-address ip-address | all-interface }**，配置可以接收和响应RADIUS授权服务器请求报文的IPv4地址。

缺省情况下，设备不接收和响应RADIUS授权服务器的所有请求报文。
- 步骤3 配置授权服务器。

步骤	命令	说明
配置 RADIUS授权服务器	radius-server authorization ip-address [vpn-instance vpn-instance-name] { server-group group-name shared-key cipher key-string shared-key cipher key-string [server-group group-name] } [protect enable]	缺省情况下，没有配置RADIUS授权服务器。

- 步骤4 （可选）执行命令**radius-server authorization match-type { any | all }**，配置设备对收到的CoA请求报文或DM请求报文中的RADIUS属性与设备上的用户信息进行匹配检查。

缺省情况下，设备以**any**方式对收到的CoA请求报文或DM请求报文中的RADIUS属性与设备上的用户信息进行匹配检查，即按照匹配优先级选取请求报文中的一个属性与设备上的用户信息进行匹配检查。
- 步骤5 （可选）执行命令**radius-server session-manage { ip-address [vpn-instance vpn-instance-name] shared-key cipher share-key | any }**，使能RADIUS服务器的会话管理功能。

缺省情况下，RADIUS服务器未使能会话管理功能。
- 步骤6 （可选）执行命令**radius-server session-manage server-source { ip-address ip-address | all-interface }**，配置可以接收和响应的RADIUS会话管理服务请求报文的IPv4地址。

缺省情况下，设备不接收和响应的RADIUS会话管理服务器的所有请求报文。

 说明

V300R021C00及之后版本，必须同时执行命令**radius-server session-manage server-source**和**radius-server session-manage**，RADIUS服务器的会话管理功能才能生效。

步骤7 （可选）配置解析RADIUS属性的格式。

- 执行命令**radius-server authorization calling-station-id decode-mac-format { bin | ascii { unformatted | { dot-split | hyphen-split } [common | compress] }**，配置设备解析RADIUS CoA/DM报文中RADIUS属性31（Calling-Station-Id）字段中MAC地址的格式。
- 执行命令**radius-server authorization attribute-decode-sameastemplate**，配置设备根据RADIUS服务器模板下的配置，解析RADIUS CoA/DM报文中RADIUS属性31（Calling-Station-Id）字段中MAC地址的格式。

缺省情况下，设备解析RADIUS动态授权报文里的calling-station-id属性字段中MAC地址时，直接按照MAC地址的长度解析，不关注MAC地址的格式和分隔符。

步骤8 （可选）配置封装RADIUS属性的格式。

执行命令**radius-server authorization attribute-encode-sameastemplate**，配置设备根据RADIUS服务器模板下的配置封装RADIUS CoA/DM报文的属性。

缺省情况下，未配置设备根据RADIUS服务器模板下的配置封装COA回应报文或DM回应报文中的属性。支持通过该步骤配置的RADIUS属性见**表1-34**。

表 1-34 支持配置的 RADIUS 属性

RADIUS属性	RADIUS模板下的配置命令	配置的项目
RADIUS属性1（User-Name）	radius-server user-name domain-included	用户名
RADIUS属性4（NAS-IP-Address）	radius-attribute nas-ip	NAS IP地址
RADIUS属性31（Calling-Station-Id）	calling-station-id mac-format	MAC地址的格式

步骤9 （可选）配置授权信息的生效模式。

1. 执行命令**aaa**，进入AAA视图。
2. 执行命令**authorization-modify mode { modify | overlay }**，配置授权服务器下发的用户授权信息的生效模式。

缺省情况下，授权服务器下发的用户授权信息的生效模式为**overlay**模式。

----结束

检查配置结果

执行命令**display radius-server authorization configuration**，查看RADIUS授权服务器的配置信息。

1.8.10 检查 AAA 的配置结果

操作步骤

- 执行命令**display aaa configuration**，查看AAA的概要信息。
- 执行命令**display authentication-scheme** [*authentication-scheme-name*]，查看认证方案的配置信息。
- 执行命令**display accounting-scheme** [*accounting-scheme-name*]，查看计费方案的配置信息。
- 执行命令**display service-scheme** [*name name*]，查看业务方案的配置信息。
- 执行命令**display radius-server configuration** [*template template-name*]，查看RADIUS服务器模板的配置信息。
- 执行命令**display radius-server item** { *ip-address* { *ipv4-address* | *ipv6-address* } { *accounting* | *authentication* } | *template template-name* }，查看RADIUS Server的配置信息。
- 执行命令**display radius-server** { *dead-interval* | *dead-count* | *detect-cycle* }，查看RADIUS服务器的检测周期、连续无响应的最大次数和检测周期循环次数的配置信息。
- 执行命令**display radius-server authorization configuration**，查看RADIUS授权服务器的配置信息。
- 执行命令**display radius-attribute** [*name attribute-name* | *type* { *attribute-number1* | *huawei attribute-number2* | *microsoft attribute-number3* | *dsforum attribute-number4* }]，查看设备支持的RADIUS属性。
- 执行命令**display radius-attribute** [*template template-name*] **disable**，查看设备禁用的RADIUS属性。
- 执行命令**display radius-attribute** [*template template-name*] **translate**，查看RADIUS属性转换的配置信息。
- 执行命令**display domain** [*name domain-name*]，查看域的配置信息。
- 执行命令**display radius-server accounting-stop-packet** { *all* | *ip* { *ip-address* | *ipv6-address* } }，查看RADIUS服务器的计费停止报文信息。
- 执行命令**display radius-attribute** [*template template-name*] **check**，查看RADIUS认证成功报文内必须检查的属性。
- 执行命令**display remote-user authen-fail** [*blocked* | *username username*]，查看认证失败的AAA远端认证帐号的信息。
- 执行命令**display aaa statistics access-type-authenreq**，查看认证请求数。
- 执行命令**display radius-server session-manage configuration**，查看RADIUS服务器会话管理功能的配置信息。

----结束

1.9 配置采用 HWTACACS 方式进行认证、授权和计费

HWTACACS 方式进行认证、授权和计费

HWTACACS协议与RADIUS协议类似，主要是通过客户端/服务器模式与HWTACACS服务器通信来实现对接入用户进行认证、授权和计费。

采用HWTACACS方式进行认证、授权、计费可以防止非法用户对网络的攻击，HWTACACS还支持对命令行进行授权，比RADIUS更适用于进行安全控制。

1.9.1 配置 HWTACACS 服务器

当用户采用HWTACACS方式认证授权时，需要将用户认证、授权以及计费等信息配置在HWTACACS服务器上。

当用户想通过某网络与接入设备建立连接，从而获得访问其它网络的权利或取得某些网络资源，接入设备负责将用户的认证、授权、计费信息透传给HWTACACS服务器。HWTACACS服务器根据配置好的信息，决定该用户是否认证通过。若该用户认证通过，则发送认证接受报文给接入设备，该报文中同时携带了用户的授权信息。接入设备根据认证接受报文信息，允许用户接入网络并授予相应权限。

1.9.2 配置 AAA 方案

背景信息

如果需要采用HWTACACS方式进行认证、授权和计费，需要在认证方案中配置认证模式为HWTACACS认证，在授权方案中配置授权模式为HWTACACS授权，在计费方案中配置计费模式为HWTACACS计费。

配置认证模式为HWTACACS认证时还可以配置本地认证或不认证为备份认证模式。配置备份认证可以避免单一认证模式无响应而造成的认证失败。同理，配置授权模式为HWTACACS授权时还可以配置本地授权或不授权为备份授权模式。

说明

如果使用`authentication-mode`命令配置认证方式为不认证，则当用户上线时，用户输入任意的用户名和密码后都会认证成功。因此，为保护设备或网络安全，建议开启认证方式，保证用户经过认证后才可以访问设备或网络。

操作步骤

- 配置认证方案
 - a. 执行命令`system-view`，进入系统视图。
 - b. 执行命令`aaa`，进入AAA视图。
 - c. 执行命令`authentication-scheme scheme-name`，创建一个认证方案，并进入认证方案视图或直接进入一个已存在的认证方案视图。

缺省情况下，设备中有两个认证方案，认证方案名称分别是default和radius，default和radius方案均不能删除，只能修改方案下的参数。
 - d. 执行命令`authentication-mode hwtacacs`，配置认证模式为HWTACACS认证。

缺省情况下，认证模式为本地认证。

如果需要配置本地认证为备份认证模式，请执行命令`authentication-mode hwtacacs [ local | local-case ]`。
 - e. （可选）执行命令`undo server no-response authorization`，配置用户在服务器认证无响应转入本地认证后，设备按照配置的授权方式授权，而不是直接请求本地授权。缺省情况下，在配置了服务器+本地的授权下，用户在服务器认证无响应转入本地认证后，设备直接请求本地认证。

- f. （可选）执行命令**undo server no-response accounting**，配置用户在服务器认证无响应转入本地认证后，设备不发送计费报文。

缺省情况下，在配置了服务器计费的情况下，用户在服务器认证无响应转入本地认证后，设备不发送计费报文。
 - g. （可选）执行命令**authentication-super { hwtaacs | super } * [none]**，在当前认证模板下，配置对用户提升级别进行认证时采用的认证模式。

缺省情况下，用户提升级别时认证模式为**super**，即本地认证模式。
 - h. 执行命令**quit**，返回AAA视图。
 - i. （可选）配置帐号锁定功能
 - i. 执行命令**access-user remote authen-fail retry-interval *retry-interval* retry-time *retry-time* block-time *block-time***，开启接入用户远端认证失败后帐号锁定功能。

或者：执行命令**administrator remote authen-fail retry-interval *retry-interval* retry-time *retry-time* block-time *block-time***，开启管理员用户远端认证失败后帐号锁定功能。

缺省情况下，接入用户远端认证失败后帐号锁定功能处于关闭状态；管理员用户远端认证失败后帐号锁定功能处于开启状态，并且，远端认证失败后用户的重试时间间隔为5分钟，连续认证失败的限制次数为30次，帐号锁定时间为5分钟。
 - ii. 执行命令**aaa-quiet administrator except-list { *ipv4-address* | *ipv6-address* } <1-32>**，配置在用户帐号锁定期间，允许该用户使用指定的IP地址访问网络。

缺省情况下，用户在帐号锁定期间不能访问网络。

通过命令**display aaa-quiet administrator except-list**，可以查询以上配置的IP地址信息。
 - iii. 执行命令**remote-user authen-fail unblock { all | *username username* }**，将认证失败的远端认证帐号解锁。
 - j. （可选）执行命令**security-name enable**，使能安全字符串功能。

缺省情况下，已使能安全字符串功能。
 - k. （可选）执行命令**domainname-parse-direction { left-to-right | right-to-left }**，配置用户名和域名解析的方向，从左向右或从右向左。

缺省情况下，域名解析方向为从左向右。
 - l. 执行命令**quit**，返回系统视图。
 - m. （可选）执行命令**aaa-authen-bypass enable time *time-value***，配置认证旁路时间。

缺省情况下，未启用旁路认证功能。
- 配置授权方案
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**aaa**，进入AAA视图。
 - c. 执行命令**authorization-scheme *authorization-scheme-name***，创建一个授权方案，并进入授权方案视图或直接进入一个已存在的授权方案视图。

缺省情况下，设备有一个授权方案，授权方案配置名是default，不能删除，只能修改。

- d. 执行命令**authorization-mode hwtacacs [local] [none]**，配置授权模式。

缺省情况下，授权模式为本地授权模式。

如果采用HWTACACS授权模式，必须配置HWTACACS服务器模板，然后在用户所属域的视图下应用该服务器模板。
- e. （可选）执行命令**authorization-cmd privilege-level hwtacacs [local] [none]**，配置某级别的用户按命令行授权。

缺省情况下，0~15级用户都没有配置按命令行授权。

如需使能按命令行授权功能，必须配置HWTACACS服务器模板，然后在用户所属域的视图下应用该服务器模板。
- f. 执行命令**quit**，返回AAA视图。
- g. 执行命令**quit**，返回系统视图。
- h. （可选）执行命令**aaa-author-bypass enable time time-value**，配置授权旁路时间。

缺省情况下，未启用旁路授权功能。
- i. （可选）执行命令**aaa-author-cmd-bypass enable time time-value**，配置命令行授权旁路时间。

缺省情况下，未启用命令行授权旁路功能。
- 配置计费方案
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**aaa**，进入AAA视图。
 - c. 执行命令**accounting-scheme accounting-scheme-name**，创建一个计费方案，并进入计费方案视图或直接进入一个已存在的计费方案视图。

缺省情况下，设备中有一个计费方案，计费方案配置名是default，不能删除，只能修改。
 - d. 执行命令**accounting-mode hwtacacs**，配置计费模式。

缺省情况下，计费模式采用不计费模式none。
 - e. （可选）执行命令**accounting start-fail { offline | online }**，配置开始计费失败策略。

缺省情况下，如果初始计费失败，不允许用户上线。
 - f. （可选）执行命令**accounting realtime interval**，使能实时计费并设置计费间隔。

缺省情况下，设备按时长计费，未使能实时计费功能。
 - g. （可选）执行命令**accounting interim-fail [max-times times] { offline | online }**，配置允许的实时计费请求最大无响应次数，以及实时计费失败后采取的策略。

缺省情况下，允许的实时计费请求最大无响应次数为3次，实时计费失败后允许用户在线。

----结束

1.9.3 配置 HWTACACS 服务器模板

背景信息

配置HWTACACS服务器模板中的关键步骤是指定服务器的IP地址和端口号、HWTACACS共享密钥。其他的步骤如配置HWTACACS用户名格式、流量单位等都有缺省配置，用户可以根据实际需要进行修改。

HWTACACS服务器模板下配置的HWTACACS用户名格式、HWTACACS共享密钥等要与HWTACACS服务器上的配置一致。

操作步骤

- 步骤1 执行命令**system-view**，进入系统视图。
- 步骤2 执行命令**hwtacacs enable**，使能HWTACACS功能。

缺省情况下，HWTACACS功能处于使能状态。
- 步骤3 执行命令**hwtacacs-server template *template-name***，创建HWTACACS服务器模板，并进入HWTACACS服务器模板视图。

缺省情况下，设备上没有HWTACACS服务器模板。
- 步骤4 配置HWTACACS认证、授权、计费服务器：

 说明

同一个HWTACACS服务器模板内，IPv4和IPv6服务器支持同时配置。同时配置时，设备选择服务器的顺序为：主IPv4服务器 -> 主IPv6服务器 -> 第二备用IPv4服务器 -> 第二备用IPv6服务器 -> 第三备用IPv4服务器 -> 第三备用IPv6服务器 -> 第四备用IPv4服务器 -> 第四备用IPv6服务器。

配置	命令	说明
配置 HWTACACS 认证服务器	- 配置IPv4服务器：hwtacacs-server authentication <i>ipv4-address</i> [<i>port</i>] [public-net vpn-instance <i>vpn-instance-name</i>] [secondary third fourth] [shared-key cipher <i>key-string</i>] - 配置IPv6服务器：hwtacacs-server authentication <i>ipv6-address</i> [<i>port</i>] [public-net vpn-instance <i>vpn-instance-name</i>] [secondary third fourth] [shared-key cipher <i>key-string</i>]	缺省情况下，未配置HWTACACS认证服务器。

配置	命令	说明
配置 HWTACACS 授权服务器	- 配置IPv4服务器：hwtacacs-server authorization <i>ipv4-address</i> [<i>port</i>] [public-net vpn-instance <i>vpn-instance-name</i>] [secondary third fourth] [shared-key cipher <i>key-string</i>] - 配置IPv6服务器：hwtacacs-server authorization <i>ipv6-address</i> [<i>port</i>] [public-net vpn-instance <i>vpn-instance-name</i>] [secondary third fourth] [shared-key cipher <i>key-string</i>]	缺省情况下，未配置HWTACACS授权服务器。
配置 HWTACACS 计费服务器	- 配置IPv4服务器：hwtacacs-server accounting <i>ipv4-address</i> [<i>port</i>] [public-net vpn-instance <i>vpn-instance-name</i>] [secondary third fourth] [shared-key cipher <i>key-string</i>] - 配置IPv6服务器：hwtacacs-server accounting <i>ipv6-address</i> [<i>port</i>] [public-net vpn-instance <i>vpn-instance-name</i>] [secondary third fourth] [shared-key cipher <i>key-string</i>]	缺省情况下，未配置HWTACACS计费服务器。

步骤5 配置与HWTACACS服务器对接选项：

步骤			命令	说明
配置 HWTACACS 服务器的共享密钥	系统视图	返回系统视图	quit	-
		配置 HWTACACS 服务器的共享密钥	hwtaacs-server shared-key cipher <i>key-string</i>	缺省情况下，没有配置 HWTACACS 服务器的共享密钥。
		进入 HWTACACS 服务器模板视图	hwtaacs-server template <i>template-name</i>	-
	HWTACACS 服务器模板视图		hwtaacs-server shared-key cipher <i>key-string</i>	缺省情况下，没有配置 HWTACACS 服务器的共享密钥。
（可选）配置设备向 HWTACACS 服务器发送的报文中用户名的格式			- 用户名包含域名：hwtaacs-server user-name domain-included - 原始用户名：hwtaacs-server user-name original - 用户名不包含域名：undo hwtaacs-server user-name domain-included	缺省情况下，设备向 HWTACACS 服务器发送的报文中的用户名为用户原始输入的用户名，设备不对其进行修改。
（可选）配置 HWTACACS 流量单位			hwtaacs-server traffic-unit { byte kbyte mbyte gbyte }	缺省情况下，设备使用字节（byte）作为 HWTACACS 流量单位。
（可选）配置设备与 HWTACACS 服务器通信的源 IP 地址			hwtaacs-server source-ip { <i>ip-address</i> source-loopback <i>interface-number</i> source-vlanif <i>interface-number</i> } 或者 hwtaacs-server source-ipv6 { <i>ipv6-address</i> source-loopback <i>interface-number</i> ipv6 source-vlanif <i>interface-number</i> }	缺省情况下，设备使用实际出方向的接口的 IP 地址作为 HWTACACS 报文的源 IP 地址。

步骤6 （可选）配置HWTACACS服务器应答超时时间和激活时间：

步骤	命令	说明
配置HWTACACS服务器应答超时时间	hwtacacs-server timer response-timeout <i>interval</i>	缺省情况下，HWTACACS应答超时时间为5秒。 如果设备在应答超时时间内，没有收到HWTACACS服务器的回复，则认为服务器不可用。此时设备将尝试使用其他方式进行认证、授权。
配置HWTACACS主服务器恢复激活时间	hwtacacs-server timer quiet <i>interval</i>	缺省情况下，主用服务器恢复激活状态前需要等待5分钟。

步骤7 （可选）执行命令**hwtacacs-server authentication user-name in-authentication-start**，配置管理员用户的认证开始报文中携带用户名。

缺省情况下，管理员用户的认证开始报文中不携带用户名。

 说明

该功能仅对管理员用户生效。

步骤8 执行命令**quit**，返回系统视图。

步骤9 （可选）执行命令**hwtacacs-server accounting-stop-packet resend { disable | enable number }**，配置计费结束报文的重传功能。

缺省情况下，设备启用计费结束报文的重传功能，报文的重传次数为100。

步骤10 执行命令**return**，返回用户视图。

步骤11 （可选）执行命令**hwtacacs-user change-password hwtacacs-server template-name**，修改用户在HWTACACS服务器上保存的用户密码。

 说明

为充分保证设备安全，请用户定期修改密码。

步骤12 （可选）执行命令**test-aaa user-name user-password hwtacacs-template template-name [accounting [start | realtime | stop]]**，测试设备与认证服务器或计费服务器的连通性，测试某个用户是否能够通过HWTACACS认证或计费。

----结束

1.9.4 （可选）配置记录方案

背景信息

使用HWTACACS方式进行认证、授权时，管理员用户对设备进行配置过程中，可能会由于错误的操作引起网络故障。通过在服务器上记录相关配置信息，当网络出现故障时，可以根据服务器上的记录信息进行故障定位。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**aaa**，进入AAA视图。

步骤3 执行命令**recording-scheme** *recording-scheme-name*，创建一个记录方案，并进入记录方案视图。

缺省情况下，设备中没有记录方案。

步骤4 执行命令**recording-mode hwtaacs** *template-name*，配置与记录方案相关联的HWTACACS服务器模板。

缺省情况下，记录方案没有与HWTACACS服务器模板相关联。

步骤5 执行命令**quit**，返回AAA视图。

步骤6 执行命令**cmd recording-scheme** *recording-scheme-name*，配置记录方案的记录策略，记录用户在设备上执行过的命令。

缺省情况下，不记录用户在设备上执行过的命令。

步骤7 执行命令**outbound recording-scheme** *recording-scheme-name*，配置记录方案的记录策略，配置记录连接信息。

缺省情况下，不记录连接信息。

步骤8 执行命令**system recording-scheme** *recording-scheme-name*，配置记录方案的记录策略，记录设备的系统级事件。

缺省情况下，不记录系统级事件。

----结束

1.9.5 配置业务方案

背景信息

用户需要获取授权信息才能上线，可以通过配置业务方案管理用户的授权信息。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**aaa**，进入AAA视图。

步骤3 执行命令**service-scheme** *service-scheme-name*，创建一个业务方案并进入业务方案视图。

缺省情况下，设备中没有创建业务方案。

步骤4 执行命令**admin-user privilege level** *level*，配置用户可以作为管理员登录设备，同时指定登录时的管理员级别。

*level*参数的取值范围是0～15。缺省情况下，未配置用户级别。

步骤5 配置相关服务器信息。

步骤	命令	说明
配置DHCP服务器组	dhcp-server group <i>group-name</i>	缺省情况下，业务方案下没有配置DHCP服务器组。
配置DNS主用服务器地址	dns <i>ip-address</i>	缺省情况下，业务方案下没有配置DNS主用服务器。
配置DNS备用服务器地址	dns <i>ip-address</i> secondary	缺省情况下，业务方案下没有配置DNS备用服务器。

步骤6 配置Efficient VPN场景下，Server端推送的资源。

步骤	命令	说明
配置wins主用服务器	wins <i>ip-address</i>	缺省情况下，业务方案下没有配置wins主用服务器。
配置wins备用服务器	wins <i>ip-address</i> secondary	缺省情况下，业务方案下没有配置wins备用服务器。
配置业务方案下的URL路径及版本号	auto-update url <i>url-string</i> version <i>version-number</i>	缺省情况下，业务方案下没有配置URL路径及版本号。
配置业务方案下的DNS缺省域名	dns-name <i>domain-name</i>	缺省情况下，业务方案下没有配置DNS缺省域名。
配置推送给对端的本端子网信息	route set acl <i>acl-number</i>	缺省情况下，未配置推送给对端的本端子网信息。
配置推送给对端的绑定IPSec的接口IP地址	route set interface	缺省情况下，未配置推送给对端的绑定IPSec的接口IP地址。

步骤7 执行命令**ip-pool** *pool-name* [**move-to** *new-position*]，配置业务方案下的IP地址池或者移动已配置的地址池的位置。

缺省情况下，业务方案下没有配置IP地址池。

 说明

配置前请确保IP地址池已经配置。

步骤8 执行命令**qos-profile profile-name**，绑定QoS模板。

缺省情况下，业务方案中没有绑定QoS模板。

 说明

配置前请确保QoS模板已经配置。

步骤9 执行命令**idle-cut idle-time flow-value [inbound | outbound]**，使能域用户的闲置切断功能并配置对应的闲置切断参数。

缺省情况下，域用户的闲置切断功能处于未使能状态。

 说明

闲置切断时间和闲置切断流量阈值是闲置切断功能生效的两个必要条件。其中，闲置切断流量阈值只能通过命令**idle-cut idle-time flow-value**配置；闲置切断时间可以使用设备上配置的数值（即参数**idle-time**）也可以使用RADIUS服务器授权的数值（由第28号RADIUS属性Idle-Timeout携带），两者同时存在时，RADIUS服务器授权的优先级高。

业务方案视图下的命令**idle-cut**，仅PPPoE用户和Portal用户生效。

----结束

1.9.6 在域下应用 AAA 方案

背景信息

创建的认证方案、授权方案、计费方案、HWTACACS服务器模板，只有在域下应用后才能生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**aaa**，进入AAA视图。

步骤3 执行命令**domain domain-name [domain-index domain-index]**，创建域并进入域视图或进入一个已存在的域视图。

缺省情况下，设备存在两个域：“default”和“default_admin”。“default”用于普通接入用户的域，“default_admin”用于管理员的域。

 说明

- 用户认证时，如果输入不带域名的用户名，将到默认域认证，因此设备需通过**domain domain-name [admin]**命令设置**domain-name**为全局默认域。
- 用户认证时，如果输入带域名的用户名，需要带上正确的域名**domain-name**。

步骤4 配置域的AAA方案：

步骤	命令	说明
配置域的认证方案	authentication-scheme scheme-name	缺省情况下，“default”域使用名为“radius”的认证方案，“default_admin”域使用名为“default”的认证方案，其他域使用名为“radius”的认证方案。

步骤	命令	说明
配置域的授权方案	authorization-scheme <i>authorization-scheme-name</i>	缺省情况下，域下没有绑定授权方案。
配置域的计费方案	accounting-scheme <i>accounting-scheme-name</i>	缺省情况下，域使用名为“default”的计费方案。“default”计费方案的策略为：计费模式为不计费，关闭实时计费开关。

步骤5 配置域的业务方案、HWTACACS服务器模板：

步骤	命令	说明
（可选）配置域的业务方案	service-scheme <i>service-scheme-name</i>	缺省情况下，域下没有配置任何业务方案。
配置域的HWTACACS服务器模板	hwtacacs-server <i>template-name</i>	缺省情况下，没有配置域的HWTACACS服务器模板。

步骤6 （可选）配置域의其它功能：

步骤	命令	说明
配置域的状态	state { active block [time-range <i>time-name</i> &<1-4>] }	当域处于阻塞状态时，属于该域的用户不能登录。缺省情况下，域创建后处于激活状态。
配置对域下的用户下发用户组授权	user-group <i>group-name</i>	缺省情况下，未配置对域下的用户下发用户组授权。

步骤7 （可选）执行命令**statistic enable**，使能域用户的流量统计功能。

缺省情况下，域用户的流量统计功能处于未使能状态。

步骤8 （可选）配置域名解析方案（如果在AAA视图和认证模板视图下都配置了域名解析，则优先使用认证模板上的配置。认证模板下的配置仅适用于无线用户）：

步骤	命令	说明
A A A 视图	quit	-

步骤		命令	说明
	配置域名解析的方向	domainname-parse-direction { left-to-right right-to-left }	域名解析的方向可以是 从左到右，或者从右到左。 缺省情况下，域名解析方向为从左到右。
	配置域名分隔符	domain-name-delimiter <i>delimiter</i>	域名分隔符可以是 \ / : < > @ ' % 中的某一个。 缺省情况下，域名分隔符为 @。
	配置域名的位置	domain-location { after-delimiter before-delimiter }	缺省情况下，域名在分隔符后。
	配置安全字符串分隔符	security-name-delimiter <i>delimiter</i>	缺省情况下，安全字符串分隔符为 *。

----结束

1.9.7 检查 AAA 的配置结果

操作步骤

- 执行命令**display aaa configuration**，查看AAA的概要信息。
- 执行命令**display authentication-scheme** [*authentication-scheme-name*]，查看认证方案的配置信息。
- 执行命令**display authorization-scheme** [*authorization-scheme-name*]，查看授权方案的配置信息。
- 执行命令**display accounting-scheme** [*accounting-scheme-name*]，查看计费方案的配置信息。
- 执行命令**display recording-scheme** [*recording-scheme-name*]，查看记录方案的配置信息。
- 执行命令**display service-scheme** [**name** *name*]，查看业务方案的配置信息。
- 执行命令**display hwtacacs-server template** [*template-name*]，查看HWTACACS服务器模板的配置信息。
- 执行命令**display hwtacacs-server template** *template-name* **verbose**，查看HWTACACS认证、计费、授权的统计信息。
- 执行命令**display hwtacacs-server accounting-stop-packet** { **all** | *number* | **ip** { *ipv4-address* | *ipv6-address* } }，查看HWTACACS服务器的计费停止报文信息。
- 执行命令**display domain** [**name** *domain-name*]，查看域的配置信息。
- 执行命令**display aaa statistics access-type-authenreq**，查看认证请求数。

----结束

1.10 配置采用 HACA 方式进行认证

HACA 方式进行认证

HACA协议与RADIUS协议类似，主要是通过客户端/服务器模式来实现对接入用户进行认证。

1.10.1 配置 HACA 服务器

背景信息

当用户采用HACA方式进行认证、授权时，需要将用户认证、授权等信息配置在HACA服务器上。

当用户进行认证时，接入设备负责将用户的认证信息发送给HACA服务器。HACA服务器根据配置好的信息，决定该用户是否认证通过。若该用户认证通过，则发送认证接受报文给接入设备，该报文中同时携带了用户的授权信息。接入设备根据认证接受报文信息，允许用户接入网络并授予访问权限。

操作步骤

请参考HACA服务器的配套资料，获取HACA服务器的配置方法。

1.10.2 配置 AAA 方案

背景信息

如果需要采用HACA方式进行认证，需要在认证方案中配置认证模式为HACA认证，在计费方案中配置计费模式为HACA计费。

说明

如果使用`authentication-mode`命令配置认证方式为不认证，则当用户上线时，用户输入任意的用户名和密码后都会认证成功。因此，为保护设备或网络安全，建议开启认证方式，保证用户经过认证后才可以访问设备或网络。

操作步骤

- 配置认证方案
 - a. 执行命令`system-view`，进入系统视图。
 - b. 执行命令`aaa`，进入AAA视图。
 - c. 执行命令`authentication-scheme scheme-name`，创建一个认证方案，并进入认证方案视图或直接进入一个已存在的认证方案视图。

缺省情况下，设备中有两个认证方案，认证方案名称分别是default和radius，default和radius方案均不能删除，只能修改方案下的参数。
 - d. 执行命令`authentication-mode haca`，配置认证模式为HACA认证。

缺省情况下，认证模式为本地认证。

如果需要配置本地认证为备份认证模式，请执行命令**authentication-mode haca local | local-case** }。

说明

如果在一个认证方案中使用多种认证模式，则认证模式的执行顺序为配置的先后顺序。只有在当前认证模式没有响应的情况下，才会采用下一种认证模式；如果在当前认证模式认证失败，则不会跳转到下一个认证模式进行认证。

- e. （可选）执行命令**undo server no-response authorization**，配置用户在服务器认证无响应转入本地认证后，设备按照配置的授权方式授权，而不是直接请求本地授权。缺省情况下，在配置了服务器+本地的授权下，用户在服务器认证无响应转入本地认证后，设备直接请求本地认证。
- f. （可选）执行命令**undo server no-response accounting**，配置用户在服务器认证无响应转入本地认证后，设备不发送计费报文。

缺省情况下，在配置了服务器计费的情况下，用户在服务器认证无响应转入本地认证后，设备不发送计费报文。

- g. 执行命令**quit**，返回AAA视图。

- h. （可选）配置帐号锁定功能

- i. 执行命令**access-user remote authen-fail retry-interval *retry-interval* retry-time *retry-time* block-time *block-time***，开启接入用户远端认证失败后帐号锁定功能。

或者：执行命令**administrator remote authen-fail retry-interval *retry-interval* retry-time *retry-time* block-time *block-time***，开启管理员用户远端认证失败后帐号锁定功能。

缺省情况下，接入用户远端认证失败后帐号锁定功能处于关闭状态；管理员用户远端认证失败后帐号锁定功能处于开启状态，并且，远端认证失败后用户的重试时间间隔为5分钟，连续认证失败的限制次数为30次，帐号锁定时间为5分钟。

- ii. 执行命令**aaa-quiet administrator except-list { *ipv4-address* | *ipv6-address* } &<1-32>**，配置在用户帐号锁定期间，允许该用户使用指定的IP地址访问网络。

缺省情况下，用户在帐号锁定期间不能访问网络。

通过命令**display aaa-quiet administrator except-list**，可以查询以上配置的IP地址信息。

- iii. 执行命令**remote-user authen-fail unblock { all | username *username* }**，将认证失败的远端认证帐号解锁。

- i. （可选）执行命令**domainname-parse-direction { left-to-right | right-to-left }**，配置域名解析的方向，从左向右或从右向左。

缺省情况下，域名解析方向为从左向右。

- j. 执行命令**quit**，返回系统视图。

- 配置计费方案

- a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**aaa**，进入AAA视图。
 - c. 执行命令**accounting-scheme *accounting-scheme-name***，创建一个计费方案，并进入计费方案视图或直接进入一个已存在的计费方案视图。

缺省情况下，设备中有一个计费方案，计费方案配置名是default，不能删除，只能修改。

- d. 执行命令**accounting-mode haca**，配置计费模式。
缺省情况下，计费模式采用不计费模式**none**。
- e. （可选）执行命令**accounting start-fail { offline | online }**，配置开始计费失败策略。
缺省情况下，如果初始计费失败，不允许用户上线。
- f. （可选）执行命令**accounting realtime interval**，使能实时计费并设置计费间隔。
缺省情况下，设备按时长计费，未使能实时计费功能。
- g. （可选）执行命令**accounting interim-fail [max-times times] { offline | online }**，配置允许的实时计费请求最大无响应次数，以及实时计费失败后采取的策略。
缺省情况下，允许的实时计费请求最大无响应次数为3次，实时计费失败后允许用户在线。

----结束

1.10.3 配置 HACA 服务器模板

背景信息

配置HACA服务器模板中的关键步骤是指定服务器的IP地址和端口号。其他的步骤如配置HACA用户名格式、HACA服务器应答超时时间等都有缺省配置，用户可以根据实际需要进行修改。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**haca-server template template-name**，创建HACA服务器模板，并进入HACA服务器模板视图。
缺省情况下，未创建HACA服务器模板。
- 步骤3** 执行命令**haca-server server-address ip-address [port] pki-realm-name**，配置HACA服务器的IP地址和端口等信息。
缺省情况下，未配置HACA服务器的IP地址和端口等信息。
- 步骤4** 执行命令**haca-server user-name domain-included**，配置设备向HACA服务器发送的报文中的用户名包含域名；或者执行命令**haca-server user-name original**，配置设备向HACA服务器发送的报文中的用户名为用户原始输入的用户名。
缺省情况下，设备向HACA服务器发送的报文中的用户名为用户原始输入的用户名。
- 步骤5** 执行命令**haca-server source-ip ip-address**，配置HACA报文的源IP地址。
缺省情况下，未配置HACA报文的源IP地址，此时设备使用实际出接口的IP地址作为HACA报文的源IP地址。
- 步骤6** （可选）执行命令**haca-server timer response-timeout interval**，配置HACA服务器应答超时时间。
缺省情况下，HACA服务器应答超时时间为5秒。

步骤7 （可选）执行命令**`haca-server timer down-delay interval`**，配置HACA服务器中断延迟时间。

缺省情况下，HACA服务器中断延迟时间为30秒。

步骤8 （可选）执行命令**`haca-server timer reconnection interval`**，配置HACA服务器重连时间间隔。

缺省情况下，HACA服务器重连时间间隔为1分钟。

步骤9 （可选）执行命令**`haca-server timer heart-beat interval`**，配置心跳报文发送周期。

缺省情况下，心跳报文发送周期为5分钟。

步骤10 （可选）执行命令**`haca-server timer register-sync interval`**，配置设备定时向CloudCampus@AC-Campus发送HACA注册同步报文的时间间隔。

缺省情况下，设备定时向CloudCampus@AC-Campus发送HACA注册同步报文的时间间隔为15分钟。

步骤11 （可选）执行命令**`haca-server accounting-stop-packet resend [ resend-times ]`**，配置允许重发计费停止报文，以及可重发的计费停止报文个数。

缺省情况下，允许重发计费停止报文，且计费停止报文的重发次数为3。

步骤12 执行命令**`haca enable`**，使能HACA功能。

缺省情况下，HACA功能处于未使能状态。

步骤13 执行命令**`quit`**，返回系统视图。

步骤14 （可选）执行命令**`haca-server timer user-syn interval`**，配置HACA服务器用户信息同步时间间隔。

缺省情况下，HACA服务器用户信息同步时间间隔为10分钟。

----结束

1.10.4 配置业务方案

背景信息

用户需要获取授权信息才能上线，可以通过配置业务方案管理用户的授权信息。

操作步骤

步骤1 执行命令**`system-view`**，进入系统视图。

步骤2 执行命令**`aaa`**，进入AAA视图。

步骤3 执行命令**`service-scheme service-scheme-name`**，创建一个业务方案并进入业务方案视图。

缺省情况下，设备中没有创建业务方案。

步骤4 执行命令**`admin-user privilege level level`**，配置用户可以作为管理员登录设备，同时指定登录时的管理员级别。

*level*参数的取值范围是0~15。缺省情况下，未配置用户级别。

步骤5 配置相关服务器信息。

步骤	命令	说明
配置DHCP服务器组	dhcp-server group <i>group-name</i>	缺省情况下，业务方案下没有配置DHCP服务器组。
配置DNS主用服务器地址	dns <i>ip-address</i>	缺省情况下，业务方案下没有配置DNS主用服务器。
配置DNS备用服务器地址	dns <i>ip-address</i> secondary	缺省情况下，业务方案下没有配置DNS备用服务器。

步骤6 配置Efficient VPN场景下，Server端推送的资源。

步骤	命令	说明
配置wins主用服务器	wins <i>ip-address</i>	缺省情况下，业务方案下没有配置wins主用服务器。
配置wins备用服务器	wins <i>ip-address</i> secondary	缺省情况下，业务方案下没有配置wins备用服务器。
配置业务方案下的URL路径及版本号	auto-update url <i>url-string</i> version <i>version-number</i>	缺省情况下，业务方案下没有配置URL路径及版本号。
配置业务方案下的DNS缺省域名	dns-name <i>domain-name</i>	缺省情况下，业务方案下没有配置DNS缺省域名。
配置推送给对端的本端子网信息	route set acl <i>acl-number</i>	缺省情况下，未配置推送给对端的本端子网信息。
配置推送给对端的绑定IPSec的接口IP地址	route set interface	缺省情况下，未配置推送给对端的绑定IPSec的接口IP地址。

步骤7 执行命令**ip-pool** *pool-name* [**move-to** *new-position*]，配置业务方案下的IP地址池或者移动已配置的地址池的位置。

缺省情况下，业务方案下没有配置IP地址池。

说明

配置前请确保IP地址池已经配置。

步骤8 执行命令**qos-profile profile-name**，绑定QoS模板。

缺省情况下，业务方案中没有绑定QoS模板。

说明

配置前请确保QoS模板已经配置。

步骤9 执行命令**idle-cut idle-time flow-value [inbound | outbound]**，使能域用户的闲置切断功能并配置对应的闲置切断参数。

缺省情况下，域用户的闲置切断功能处于未使能状态。

说明

闲置切断时间和闲置切断流量阈值是闲置切断功能生效的两个必要条件。其中，闲置切断流量阈值只能通过命令**idle-cut idle-time flow-value**配置；闲置切断时间可以使用设备上配置的数值（即参数**idle-time**）也可以使用RADIUS服务器授权的数值（由第28号RADIUS属性Idle-Timeout携带），两者同时存在时，RADIUS服务器授权的优先级高。

业务方案视图下的命令**idle-cut**，仅PPPoE用户和Portal用户生效。

---结束

1.10.5 在域下应用 AAA 方案

背景信息

创建的认证方案和HACA服务器模板，只有在域下应用后才能生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**aaa**，进入AAA视图。

步骤3 执行命令**domain domain-name**，创建域并进入域视图或直接进入一个已存在的域视图。

缺省情况下，设备上存在名为“default”和“default_admin”两个域。可以修改这两个域下的配置，但是不能删除这两个域。

步骤4 执行命令**authentication-scheme authentication-scheme-name**，配置域的认证方案。

缺省情况下，“default”域使用名为“radius”的认证方案，“default_admin”域使用名为“default”的认证方案，其他域使用名为“radius”的认证方案。

步骤5 执行命令**accounting-scheme accounting-scheme-name**，配置域的计费方案。

缺省情况下，域使用名为“default”的计费方案。“default”计费方案的策略为：计费模式为不计费，关闭实时计费开关。

步骤6 执行命令**service-scheme service-scheme-name**，配置域的业务方案。

缺省情况下，域下没有绑定任何业务方案。

- 步骤7** 执行命令**haca-server *template-name***，配置域的HACA服务器模板。
- 缺省情况下，没有配置域的HACA服务器模板。
- 步骤8** （可选）执行命令**state { active | block [*time-range time-name* &<1-4>] }**，配置域的状态。
- 缺省情况下，域创建后处于激活状态。当域处于阻塞状态时，属于该域的用户不能登录。
- 步骤9** （可选）配置域名解析方案（如果在AAA视图和认证模板视图下都配置了域名解析，则优先使用认证模板上的配置。认证模板下的配置仅适用于无线用户）：

步骤		命令	说明
A A A 视 图	退出域视图	quit	-
	配置域名解析的方向	domainname-parse-direction { left-to-right right-to-left }	域名解析的方向可以是 从左到右，或者从右到左。 缺省情况下，域名解析方向为从左到右。
	配置域名分隔符	domain-name-delimiter <i>delimiter</i>	域名分隔符可以是 \ / : < > @ ' % 中的某一个。 缺省情况下，域名分隔符为@。
	配置域名的位置	domain-location { after-delimiter before-delimiter }	缺省情况下，域名在分隔符后。
	配置安全字符串分隔符	security-name-delimiter <i>delimiter</i>	缺省情况下，安全字符串分隔符为*。

----结束

1.10.6 检查配置结果

操作步骤

- 执行命令**display haca-server configuration [*template template-name*]**，查看HACA服务器模板的配置信息。
- 执行命令**display haca-server statistics { all | message | packet [authentication | authorization | accounting | cut-notify | cut-request | register | user-syn] } [*template template-name*]**，查看HACA报文统计信息。

- 执行命令**display haca-server accounting-stop-packet all**，查看HACA服务器的所有计费停止报文信息。

----结束

1.11 维护 AAA

1.11.1 强制在线用户下线

背景信息

当在线用户为非法用户、在线用户数达到最大值或者需要修改AAA业务时，可以通过指定域名或接口等方式强制在线用户下线。例如，对在线用户的AAA配置进行修改时，必须强制在线用户下线新的AAA配置才会生效。

说明

如果对在线用户的AAA配置进行删除，则可能导致该在线用户被强制下线。

操作步骤

- 在AAA视图下执行命令**cut access-user { domain domain-name | interface interface-type interface-number [vlan vlan-id [qinq qinq-vlan-id]] | ip-address ip-address [vpn-instance vpn-instance-name] | mac-address mac-address | service-scheme service-scheme-name | access-slot slot-id | ssid ssid-name | user-group group-number | user-id begin-number [end-number] | username user-name }**或执行命令**cut access-user access-type { admin [ftp | ssh | telnet | terminal | web] | ppp | l2tp } [username user-name]**，切断一个或多个会话连接，即强制在线用户下线。

----结束

1.11.2 测试单个用户能否通过 RADIUS 认证或计费

前提条件

配置RADIUS方式进行认证或计费。

说明

如果采用HWTACACS认证或计费方式，可以执行命令**test-aaa user-name user-password hwtacacs-template template-name [accounting [start | realtime | stop]]**，测试设备与认证服务器或计费服务器的连通性。

背景信息

测试单个用户能否通过RADIUS认证或计费，方便管理员进行进一步的故障定位。

操作步骤

- 任意视图下执行命令**test-aaa user-name user-password radius-template template-name [chap | pap]**，测试单个用户是否能够通过RADIUS认证。

- 任意视图下执行命令**test-aaa user-name user-password radius-template template-name [accounting [start | realtime | stop]]**，测试单个用户是否能够通过RADIUS计费。

----结束

后续处理

- 执行命令**test-aaa**后返回超时
测试单个用户能否通过RADIUS认证返回超时

```
<Huawei> test-aaa user1 test123 radius-template test
```

```
Info: Account test time out.
```


测试单个用户能否通过RADIUS计费返回超时

```
<Huawei> test-aaa user1 test123 radius-template test accounting
```

```
Info: Account test time out.
```

 - 可能的原因有：
 - 设备和服务器之间的路由不可达。
 - RADIUS服务器模板内配置的NAS-IP与RADIUS服务器上不一致。
 - RADIUS服务器模板内配置的认证或计费端口号错误。
 - RADIUS服务器上的认证或计费端口被其他程序占用。
 - RADIUS服务器模板内的RADIUS服务器地址不正确。
 - 接入控制设备IP地址配置错误或者是RADIUS服务器未启动。
 - 处理步骤：
 - 执行命令**ping**，检查设备和服务器之间的路由是否可达。
 - 在任意视图下执行命令**display radius-server configuration [template template-name]**，检查RADIUS服务器模板内配置的端口号是否和RADIUS服务器中端口号一致、NAS-IP与RADIUS服务器上是否一致。
 - 检查RADIUS服务器认证端口号是否为1812，计费端口号是否为1813。
 - 使用控制器作RADIUS服务器时，在服务器上运行**netstat -nao | findstr 1812**和**netstat -nao | findstr 1813**命令，查看该端口是否被其他程序占用，若被占用，则将占用端口的程序关闭。
 - 检查接入控制设备IP地址配置是否正确。
- 执行命令**test-aaa**后返回帐号测试失败
测试单个用户能否通过RADIUS认证返回帐号测试失败

```
<Huawei> test-aaa user1 test123 radius-template test
```

```
Info: Account test failed.
```


测试单个用户能否通过RADIUS计费返回帐号测试失败

```
<Huawei> test-aaa user1 test123 radius-template test accounting
```

```
Info: Account test failed.
```

 - 可能的原因有：
 - 未配置RADIUS服务器共享密钥。

- 未配置RADIUS服务器IP地址。
- 处理步骤：
 - 在任意视图下执行命令**display radius-server configuration [template template-name]**，检查RADIUS服务器模板内是否配置了共享密钥与IP地址。
- 执行命令**test-aaa**后测试结果通过而该用户登录时无法通过认证或计费
 - 可能的原因有：
 - 设备和服务器之间的路由不可达。
 - 用户认证或计费时使用的域与设备配置RADIUS认证或计费的域是否一致。
 - 处理步骤：
 - 执行命令**ping**，检查用户与设备之间路由是否可达。
 - 在AAA视图下执行命令**display this**，检查用户认证时使用的域与设备配置RADIUS认证或计费的域是否一致。
 - 用户输入的用户名包含域名时，检查RADIUS认证或计费是否在该域名对应的域下配置。
 - 用户输入的用户名不包含域名时，检查RADIUS认证或计费是否在全局默认域（管理用户使用全局默认管理域default_admin，普通用户使用全局默认普通域default）下配置。
 - 在AAA视图下执行命令**display this**，检查域下是否引用了AAA认证或计费方案和RADIUS服务器模板。
 - 如果配置了NAC，请检查NAC配置是否正确。

1.11.3 配置 AAA 告警上报功能

背景信息

为了方便运维，及时了解网络中AAA的运行状态，可以配置AAA告警上报功能，将AAA运行的状态变化情况（例如，RADIUS计费服务器通讯状态由UP变为DOWN）通知给网管系统，提醒管理员进行查看。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**snmp-agent trap enable feature-name radius [trap-name { hwradiusacctserverdown | hwradiusacctserverup | hwradiusauthserverdown | hwradiusauthserverup }]**，打开RDS模块的告警开关。

缺省情况下，RDS模块的告警开关处于关闭状态。

----结束

检查配置结果

执行命令**display snmp-agent trap feature-name radius all**，查看RDS模块的所有告警开关的信息。

1.11.4 记录用户上、下线信息

背景信息

为了方便管理员定位和分析用户上线失败、异常下线的原因为，可以使能记录用户正常下线、异常下线、上线失败信息功能。

操作步骤

- 在系统视图下执行命令**aaa offline-record**，使能记录用户正常下线信息的功能。
缺省情况下，已使能记录用户正常下线信息的功能。
- 在系统视图下执行命令**aaa abnormal-offline-record**，使能记录用户异常下线信息的功能。
缺省情况下，已使能记录用户异常下线信息的功能。
- 在系统视图下执行命令**aaa online-fail-record**，使能记录用户上线失败信息的功能。
缺省情况下，已使能记录用户上线失败信息的功能。

----结束

后续处理

- 在任意视图下执行命令**display aaa { offline-record | abnormal-offline-record | online-fail-record } { all | reverse-order | domain domain-name | interface interface-type interface-number [vlan vlan-id [qinq qinq-vlan-id]] | ip-address ip-address [vpn-instance vpn-instance-name] | mac-address mac-address | access-slot slot-number | time start-time end-time [date start-date end-date] | username user-name [time start-time end-time [date start-date end-date]] } [brief]**，查看用户正常下线、异常下线、上线失败记录信息。
- 在任意视图下执行命令**display aaa statistics offline-reason**，查看用户下线原因。

1.11.5 清除 AAA 统计信息

背景信息

须知

清除统计信息后，以前的统计信息将无法恢复，请务必仔细确认。

在确认需要清除统计信息后，请执行以下命令。

操作步骤

- 在系统视图下执行**reset aaa { abnormal-offline-record | offline-record | online-fail-record }**命令清除用户异常下线、用户下线、上线失败的记录信息。
- 在任意视图下执行**reset aaa statistics offline-reason**命令清除用户下线的原因统计信息。
- 在任意视图下执行**reset access-user statistics**命令清除接入用户认证相关统计信息。
- 在用户视图下执行**reset hwtacacs-server statistics { accounting | all | authentication | authorization }**命令清除HWTACACS认证、计费、授权的统计信息。
- 在用户视图下执行**reset hwtacacs-server accounting-stop-packet { all | ip { ipv4-address | ipv6-address } }**命令清除HWTACACS计费停止报文剩余的缓存信息。
- 在用户视图下执行**reset radius-server accounting-stop-packet { all | ip { ipv4-address | ipv6-address } }**命令清除RADIUS计费停止报文剩余的缓存信息。
- 在AAA视图下执行**reset local-user [user-name] password history record**命令清除本地用户的密码历史记录。
- 在任意视图下执行**reset aaa statistics access-type-authenreq**命令清除认证请求数。

----结束

1.11.6 清除 HACA 统计信息

背景信息

定位问题时，可能需要获取某一时间内报文的统计信息，在开始统计前需要清除原有的统计信息。

须知

清除统计信息后，以前的统计信息将无法恢复，请务必仔细确认。

操作步骤

- 在用户视图下执行命令**reset haca-server statistics { all | message | packet [register | accounting | authentication | authorization | user-syn | cut-notify | cut-request] } [template template-name]**，清除HACA报文的统计信息。
- 在用户视图下执行命令**reset haca-server accounting-stop-packet all**，清除所有HACA计费停止报文剩余的缓存信息。

----结束

1.12 AAA 配置举例

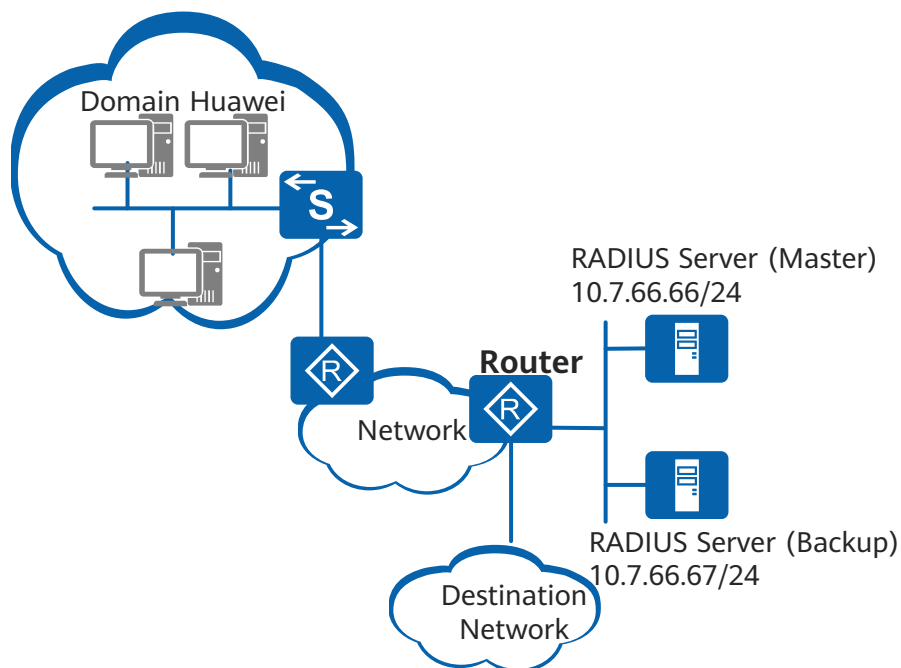
1.12.1 配置主备 RADIUS 服务器示例

组网需求

如图1-29所示，用户同处于huawei域，Router作为目的网络接入服务器。用户需要通过服务器的远端认证才能通过Router访问目的网络。在Router上的远端认证方式如下：

- Router对接入用户先用RADIUS服务器进行认证，如果认证没有响应，再使用本地认证。
- RADIUS服务器10.7.66.66/24作为主用认证服务器和计费服务器，RADIUS服务器10.7.66.67/24作为备用认证服务器和计费服务器，认证端口号缺省为1812，计费端口号缺省为1813。

图 1-29 采用 RADIUS 协议对用户进行认证和计费组网图



配置思路

用如下的思路配置采用RADIUS协议对用户进行认证和计费。

1. 配置RADIUS服务器模板。
2. 配置认证方案、计费方案。
3. 在域下应用RADIUS服务器模板、认证方案和计费方案。

 说明

- 配置前请确保各设备之间路由可达。
- 请确保RADIUS服务器模板内的共享密钥和RADIUS服务器上的配置保持一致。
- 如果RADIUS服务器不接受包含域名的用户名，可以在RADIUS服务器模板视图下，配置命令**undo radius-server user-name domain-included**使设备向RADIUS服务器发送的报文中的用户名不包含域名。
- 域被配置成全局默认域之后，用户的用户名中携带该域名或者不携带域名时，会使用全局默认域下的AAA配置信息。
- 配置命令undo radius-server user-name domain-included后，设备仅会修改发送报文中的用户名格式，不会影响用户所属的域。例如，配置该命令后，用户名为“user@huawei.com”的用户仍使用huawei.com域下的AAA配置信息。

操作步骤

步骤1 配置RADIUS服务器模板。

配置RADIUS服务器模板shiva。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] radius-server template shiva
```

配置RADIUS主用认证服务器和计费服务器的IP地址、端口。

```
[Router-radius-shiva] radius-server authentication 10.7.66.66 1812 weight 80
[Router-radius-shiva] radius-server accounting 10.7.66.66 1813 weight 80
```

配置RADIUS备用认证服务器和计费服务器的IP地址、端口。

```
[Router-radius-shiva] radius-server authentication 10.7.66.67 1812 weight 40
[Router-radius-shiva] radius-server accounting 10.7.66.67 1813 weight 40
```

配置RADIUS服务器密钥、重传次数，以及设备向RADIUS服务器发送的报文中的用户名不包含域名。

```
[Router-radius-shiva] radius-server shared-key cipher YsHsjx_202206
[Router-radius-shiva] radius-server retransmit 2
[Router-radius-shiva] undo radius-server user-name domain-included
[Router-radius-shiva] quit
```

步骤2 配置认证方案、计费方案。

配置认证方案auth，认证模式为先进进行RADIUS认证，后进行本地认证。

```
[Router] aaa
[Router-aaa] authentication-scheme auth
[Router-aaa-authen-auth] authentication-mode radius local
[Router-aaa-authen-auth] quit
```

配置计费方案abc，计费模式为RADIUS，并配置当开始计费失败时，允许用户上线。

```
[Router-aaa] accounting-scheme abc
[Router-aaa-accounting-abc] accounting-mode radius
[Router-aaa-accounting-abc] accounting start-fail online
[Router-aaa-accounting-abc] quit
```

步骤3 配置huawei域，在域下应用认证方案auth、计费方案abc、RADIUS服务器模板shiva。

```
[Router-aaa] domain huawei
[Router-aaa-domain-huawei] authentication-scheme auth
[Router-aaa-domain-huawei] accounting-scheme abc
[Router-aaa-domain-huawei] radius-server shiva
```

```
[Router-aaa-domain-huawei] quit
[Router-aaa] quit
```

步骤4 配置huawei域为全局默认域。

```
[Router] domain huawei
[Router] domain huawei admin
```

步骤5 配置AAA本地认证。

```
[Router] aaa
[Router-aaa] local-user user1 password irreversible-cipher YsHsjx_202207
[Router-aaa] local-user user1 service-type http
[Router-aaa] local-user user1 privilege level 15
[Router-aaa] quit
```

步骤6 验证配置结果。

在Router上执行命令**display radius-server configuration template *template-name***，可以观察到该RADIUS服务器模板的配置与要求一致。

```
[Router] display radius-server configuration template shiva
-----
Server-template-name      : shiva
Server-template-index     : 1
Protocol-version          : standard
Traffic-unit              : B
Shared-secret-key         : *****
Group-filter              : class
Timeout-interval(in second) : 5
Retransmission            : 2
EndPacketSendTime        : 3
Dead time(in minute)      : 5
Domain-included           : NO
NAS-IP-Address            : -
Calling-station-id MAC-format : xxxx-xxxx-xxxx
Called-station-id MAC-format : XX-XX-XX-XX-XX-XX
NAS-Port-ID format        : New
Service-type              : -
NAS-IPv6-Address          : ::
Server algorithm          : master-backup
Detect-interval(in second) : 60
Authentication Server 1   : 10.7.66.66 Port:1812 Weight:80 [UP]
                          Vrf:- LoopBack:NULL Vlanif:NULL
                          Source IP: ::
Authentication Server 2   : 10.7.66.67 Port:1812 Weight:40 [UP]
                          Vrf:- LoopBack:NULL Vlanif:NULL
                          Source IP: ::
Accounting Server 1       : 10.7.66.66 Port:1813 Weight:80 [UP]
                          Vrf:- LoopBack:NULL Vlanif:NULL
                          Source IP: ::
Accounting Server 2       : 10.7.66.67 Port:1813 Weight:40 [UP]
                          Vrf:- LoopBack:NULL Vlanif:NULL
                          Source IP: ::
-----
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
domain huawei
domain huawei admin
#
radius-server template shiva
```

```
radius-server shared-key cipher %^%#BS$!w:u7H.lu:/&W9A5=pUtz3#CA>MtbD=>A]Ts;au$;&!<sN~"B!+
+2S8'--;%^%#
radius-server authentication 10.7.66.66 1812 weight 80
radius-server authentication 10.7.66.67 1812 weight 40
radius-server accounting 10.7.66.66 1813 weight 80
radius-server accounting 10.7.66.67 1813 weight 40
radius-server retransmit 2
undo radius-server user-name domain-included
#
aaa
authentication-scheme auth
authentication-mode radius local
accounting-scheme abc
accounting-mode radius
accounting start-fail online
domain huawei
authentication-scheme auth
accounting-scheme abc
radius-server shiva
local-user user1 password irreversible-cipher
local-user user1 privilege level 15
local-user user1 service-type http
#
return
```

相关资料

视频: [配置RADIUS认证和计费](#)

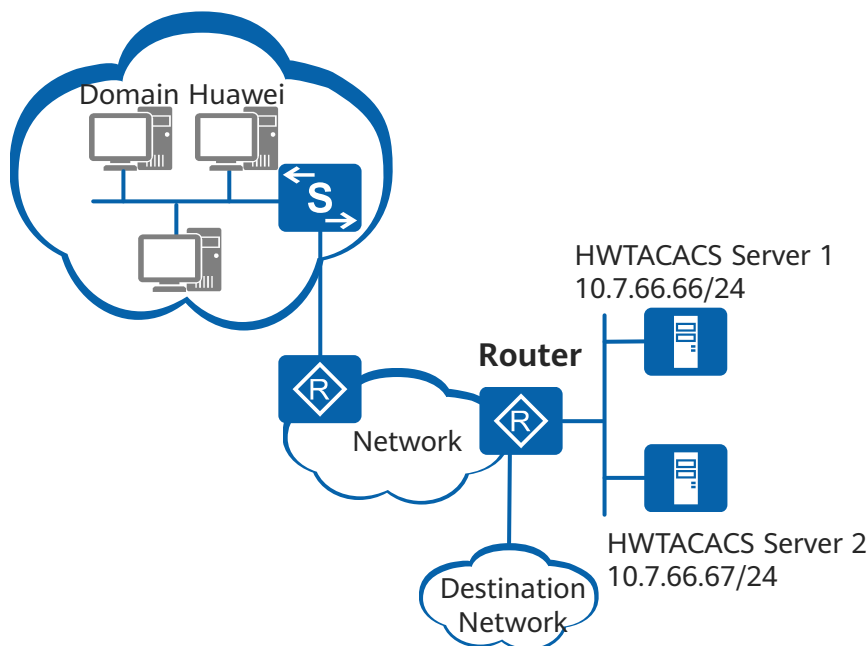
1.12.2 配置主备 HWTACACS 服务器示例

组网需求

如[图1-30](#)所示，用户要求：

- Router对接入用户先用HWTACACS服务器进行认证，如果HWTACACS服务器Down或者无响应时，再使用本地认证。
- Router对接入用户先用HWTACACS服务器进行授权，如果HWTACACS授权服务器连接失败的时候，设备无法完成HWTACACS授权，再使用本地授权。
- Router对接入用户采用HWTACACS计费。
- 对用户进行实时计费，计费间隔为3分钟。
- HWTACACS主用服务器为10.7.66.66/24，备用服务器为10.7.66.67/24，服务器的认证、授权和计费端口号均为49。

图 1-30 采用 HWTACACS 协议对用户进行认证、计费 and 授权组网图



配置思路

采用如下的思路配置对用户使用本地和HWTACACS认证、HWTACACS授权和进行实时计费。

1. 配置HWTACACS服务器模板。
2. 配置认证方案、授权方案、计费方案。
3. 在域下应用HWTACACS服务器模板、认证方案、授权方案、计费方案。

说明

- 配置前请确保各设备之间路由可达。
- 请确保HWTACACS服务器模板内的共享密钥与HWTACACS服务器上的配置保持一致。
- 如果HWTACACS服务器不接受包含域名的用户名，可以在HWTACACS服务器模板视图下，配置命令**undo hwtacacs-server user-name domain-included**使设备向HWTACACS服务器发送的报文中的用户名不包含域名。
- 域被配置成全局默认域之后，用户的用户名中携带该域名或者不携带域名时，会使用全局默认域下的AAA配置信息。
- 配置命令**undo hwtacacs-server user-name domain-included**后，设备仅会修改发送报文中的用户名格式，不会影响用户所属的域。例如，配置该命令后，用户名为“user@huawei.com”的用户仍使用huawei.com域下的AAA配置信息。

操作步骤

步骤1 使能HWTACACS功能。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] hwtacacs enable
```

 说明

设备默认已经使能HWTACACS功能，如果未修改过默认配置，可以不配置此命令。

步骤2 配置HWTACACS服务器模板。

配置HWTACACS服务器模板ht。

```
[Router] hwtacacs-server template ht
```

配置HWTACACS主用认证、授权、计费服务器的IP地址和端口。

```
[Router-hwtacacs-ht] hwtacacs-server authentication 10.7.66.66 49
```

```
[Router-hwtacacs-ht] hwtacacs-server authorization 10.7.66.66 49
```

```
[Router-hwtacacs-ht] hwtacacs-server accounting 10.7.66.66 49
```

配置HWTACACS备用认证、授权、计费服务器的IP地址和端口。

```
[Router-hwtacacs-ht] hwtacacs-server authentication 10.7.66.67 49 secondary
```

```
[Router-hwtacacs-ht] hwtacacs-server authorization 10.7.66.67 49 secondary
```

```
[Router-hwtacacs-ht] hwtacacs-server accounting 10.7.66.67 49 secondary
```

配置HWTACACS服务器密钥。

 说明

请确保HWTACACS服务器模板内的共享密钥与HWTACACS服务器上的配置保持一致。

```
[Router-hwtacacs-ht] hwtacacs-server shared-key cipher YsHsjx_202206
```

```
[Router-hwtacacs-ht] quit
```

步骤3 配置认证方案、授权方案、计费方案。

配置认证方案l-h，认证模式为先进进行HWTACACS认证，后进行本地认证。

```
[Router] aaa
```

```
[Router-aaa] authentication-scheme l-h
```

```
[Router-aaa-authen-l-h] authentication-mode hwtacacs local
```

```
[Router-aaa-authen-l-h] quit
```

配置授权方案hwtacacs，授权模式为先进进行HWTACACS授权，后进行本地授权。

```
[Router-aaa] authorization-scheme hwtacacs
```

```
[Router-aaa-author-hwtacacs] authorization-mode hwtacacs local
```

```
[Router-aaa-author-hwtacacs] quit
```

配置计费方案hwtacacs，计费模式为HWTACACS，并配置当开始计费失败时，允许用户上线。

```
[Router-aaa] accounting-scheme hwtacacs
```

```
[Router-aaa-accounting-hwtacacs] accounting-mode hwtacacs
```

```
[Router-aaa-accounting-hwtacacs] accounting start-fail online
```

配置实时计费间隔为3分钟。

```
[Router-aaa-accounting-hwtacacs] accounting realtime 3
```

```
[Router-aaa-accounting-hwtacacs] quit
```

步骤4 配置huawei域，在域下采用l-h认证方案、HWTACACS授权方案、HWTACACS计费方案、ht的HWTACACS模板。

```
[Router-aaa] domain huawei
```

```
[Router-aaa-domain-huawei] authentication-scheme l-h
```

```
[Router-aaa-domain-huawei] authorization-scheme hwtacacs
```

```
[Router-aaa-domain-huawei] accounting-scheme hwtacacs
```

```
[Router-aaa-domain-huawei] hwtacacs-server ht
```

```
[Router-aaa-domain-huawei] quit
```

```
[Router-aaa] quit
```


步骤5 配置AAA本地认证。

```
[Router] aaa
[Router-aaa] local-user user1 password irreversible-cipher YsHsjx_202206
[Router-aaa] local-user user1 service-type http
[Router-aaa] local-user user1 privilege level 15
[Router-aaa] quit
```

步骤6 配置全局默认管理域。

```
[Router] domain huawei admin
```

步骤7 验证配置结果。

在Router上执行命令**display hwtacacs-server template**，可以观察到该HWTACACS服务器模板的配置与要求一致。

```
[Router] display hwtacacs-server template ht
-----
HWTACACS-server template name : ht
Primary-authentication-server : 10.7.66.66:49:-
Primary-authorization-server : 10.7.66.66:49:-
Primary-accounting-server : 10.7.66.66:49:-
Secondary-authentication-server : 10.7.66.67:49:-
Secondary-authorization-server : 10.7.66.67:49:-
Secondary-accounting-server : 10.7.66.67:49:-
Third-authentication-server : -:0:-
Third-authorization-server : -:0:-
Third-accounting-server : -:0:-
Current-authentication-server : 10.7.66.66:49:-
Current-authorization-server : 10.7.66.66:49:-
Current-accounting-server : 10.7.66.66:49:-
Source-IP-address : -
Source-IPv6-address : ::
Shared-key : *****
Quiet-interval(min) : 5
Response-timeout-Interval(sec) : 5
Domain-included : Original
Traffic-unit : B
-----
```

同时在Router上执行命令**display domain**，可以观察到该域的配置与要求一致。

```
[Router] display domain name huawei
Domain-name : huawei
Domain-index : 2
Domain-state : Active
Authentication-scheme-name : l-h
Accounting-scheme-name : hwtacacs
Authorization-scheme-name : hwtacacs
Service-scheme-name : -
RADIUS-server-template : default
HWTACACS-server-template : ht
User-group : -
Push-url-address : -
Flow-statistic : -
Tariff-level : -
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
domain huawei admin
#
```

```
hwtacacs-server template ht
hwtacacs-server authentication 10.7.66.66
hwtacacs-server authentication 10.7.66.67 secondary
hwtacacs-server authorization 10.7.66.66
hwtacacs-server authorization 10.7.66.67 secondary
hwtacacs-server accounting 10.7.66.66
hwtacacs-server accounting 10.7.66.67 secondary
hwtacacs-server shared-key cipher %^%#0%i9M.C!T$8iTn7lg-4V8GTgK[gwp3b6;k=caxl-%^%#
#
aaa
authentication-scheme l-h
authentication-mode hwtacacs local
authorization-scheme hwtacacs
authorization-mode hwtacacs local
accounting-scheme hwtacacs
accounting-mode hwtacacs
accounting realtime 3
accounting start-fail online
domain huawei
authentication-scheme l-h
accounting-scheme hwtacacs
authorization-scheme hwtacacs
hwtacacs-server ht
local-user user1 password irreversible-cipher $1a$8&/1M*R6{A$#D_UJt7Vv1L5LI*A_!=Udl)WLj|dhD~oxy=
$O[]F$
local-user user1 privilege level 15
local-user user1 service-type http
#
return
```

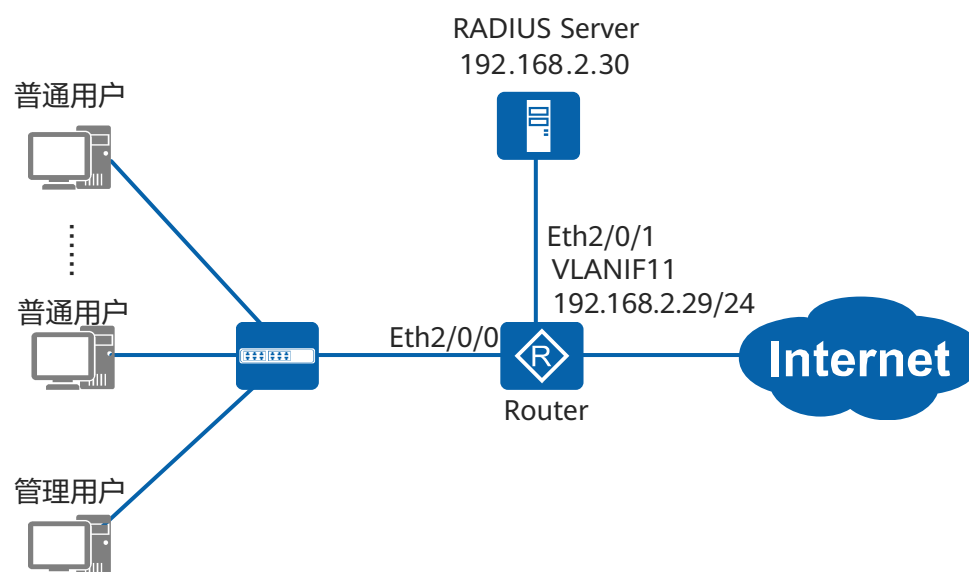
1.12.3 配置基于默认域的用户管理示例

组网需求

如图1-31所示，企业用户通过Router接入网络，用户名不带任何域名。

企业希望普通用户需要经过RADIUS认证后才能接入网络，并获取对应权限，管理用户需要经过Router的本地认证后才能登录设备进行管理。

图 1-31 配置基于默认域的用户管理组网图



配置思路

采用如下的思路配置基于默认域的用户管理：

1. 创建VLAN、VLANIF，并配置各接口，使Router与RADIUS服务器网络互通。
2. 配置普通用户的认证计费方案并应用到缺省的“default”域下，实现对不带域名的普通接入用户（例如，采用802.1X进行认证的用户）的RADIUS身份验证。
3. 配置管理用户的认证和授权方案并应用到缺省的“default_admin”域下，实现对不带域名的管理用户（例如，采用Telnet、SSH或FTP方式登录的用户）的本地身份验证。

说明

请确保已在RADIUS服务器上配置了用户，本例中假设RADIUS服务器上已配置了用户名为test1，密码为YsHsjx_202206的用户。

本案例只包括Router的配置，RADIUS服务器的配置这里不做相关说明。

操作步骤

步骤1 创建VLAN并配置各接口。

在Router上创建VLAN 11。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 11
```

配置Router连接RADIUS服务器的接口Eth2/0/1为Access类型端口，并将Eth2/0/1加入VLAN11。

```
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type access
[Router-Ethernet2/0/1] port default vlan 11
[Router-Ethernet2/0/1] quit
```

创建VLANIF11，并为VLANIF11配置IP地址192.168.2.29/24。

```
[Router] interface vlanif 11
[Router-Vlanif11] ip address 192.168.2.29 24
[Router-Vlanif11] quit
```

步骤2 配置802.1X普通用户采用RADIUS方式进行认证、授权和计费。

说明

请确保RADIUS服务器模板内的共享密钥和RADIUS服务器上的配置保持一致。

创建并配置RADIUS服务器模板“rd1”。

```
[Router] radius-server template rd1
[Router-radius-rd1] radius-server authentication 192.168.2.30 1812
[Router-radius-rd1] radius-server accounting 192.168.2.30 1813
[Router-radius-rd1] radius-server shared-key cipher YsHsjx_202207
[Router-radius-rd1] radius-server retransmit 2
[Router-radius-rd1] quit
```

分别创建AAA认证和计费方案“abc”并配置认证和计费方式为RADIUS。

```
[Router] aaa
[Router-aaa] authentication-scheme abc
[Router-aaa-authen-abc] authentication-mode radius
[Router-aaa-authen-abc] quit
[Router-aaa] accounting-scheme abc
```

```
[Router-aaa-accounting-abc] accounting-mode radius
[Router-aaa-accounting-abc] quit
```

测试Router与RADIUS服务器之间的连接状态。（已在RADIUS服务器上配置了测试用户test1，用户密码为YsHsjx_202206）

```
[Router-aaa] test-aaa test1 YsHsjx_202206 radius-template rd1
```

在缺省的“default”域上绑定AAA认证方案“abc”、AAA计费方案“abc”和RADIUS服务器模板“rd1”。

```
[Router-aaa] domain default
[Router-aaa-domain-default] authentication-scheme abc
[Router-aaa-domain-default] accounting-scheme abc
[Router-aaa-domain-default] radius-server rd1
[Router-aaa-domain-default] quit
[Router-aaa] quit
```

在接口下使能802.1X认证。

```
[Router] dot1x-access-profile name d1
[Router-dot1x-access-profile-d1] quit
[Router] authentication-profile name p1
[Router-authen-profile-p1] dot1x-access-profile d1
[Router-authen-profile-p1] authentication mode multi-authen max-user 100
[Router-authen-profile-p1] quit
[Router] vlan batch 10
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type access
[Router-Ethernet2/0/0] port default vlan 10
[Router-Ethernet2/0/0] authentication-profile p1
[Router-Ethernet2/0/0] quit
```

配置全局默认普通域为“default”。普通用户进行接入认证时，以格式“user@default”输入用户名即可在default域下进行AAA认证。如果用户名中不携带域名或携带的域名不存在，普通用户也将会默认普通域中进行认证。

```
[Router] domain default
```

步骤3 配置管理用户“test”采用本地认证方式进行认证和授权。

配置当Telnet用户通过VTY用户界面登录设备时，采用“AAA”的授权验证方式。

```
[Router] telnet server enable
[Router] user-interface vty 0 14
[Router-ui-vty0-14] authentication-mode aaa
[Router-ui-vty0-14] quit
```

创建一个名为test的本地用户，用户口令为“YsHsjx_202206”，用户级别为3。

```
[Router] aaa
[Router-aaa] local-user test password irreversible-cipher YsHsjx_202206 privilege level 3
```

配置用户test的接入类型为Telnet。

```
[Router-aaa] local-user test service-type telnet
```

使能本地帐号锁定功能并配置用户的重试时间间隔为5分钟、连续认证失败的限制次数为3次以及帐号锁定时间为5分钟。

```
[Router-aaa] local-aaa-user wrong-password retry-interval 5 retry-time 3 block-time 5
```

配置认证方案auth，认证模式为Local。

```
[Router-aaa] authentication-scheme auth
[Router-aaa-authen-auth] authentication-mode local
[Router-aaa-authen-auth] quit
```

配置授权方案autho，授权模式为Local。

```
[Router-aaa] authorization-scheme autho
[Router-aaa-author-autho] authorization-mode local
[Router-aaa-author-autho] quit
```

配置default_admin域，在域下应用认证方案auth、授权方案autho。

```
[Router-aaa] domain default_admin
[Router-aaa-domain-default_admin] authentication-scheme auth
[Router-aaa-domain-default_admin] authorization-scheme autho
[Router-aaa-domain-default_admin] quit
[Router-aaa] quit
```

配置全局默认管理域为“default_admin”。管理用户进行认证时，以格式“user@default_admin”输入用户名即可在default_admin域下进行AAA认证。如果用户名中不携带域名或携带的域名不存在，管理用户也将会在默认管理域中进行认证。

```
[Router] domain default_admin admin
[Router] quit
```

步骤4 验证配置结果。

在Router上执行命令**display dot1x interface**，可以查看到802.1X认证的相关信息。

当普通用户上线时，在802.1X客户端输入用户名**test1**和密码**YsHsjx_202206**后，在设备上可以通过**display access-user domain**和**display access-user user-id**命令查看用户所属的域和接入类型。

```
<Router> display access-user domain default
-----
UserID Username      IP address      MAC             Status
-----
16040 test1          -               00e0-fc01-31f6  Success
-----
Total: 1, printed: 1
<Router> display access-user user-id 16040
Basic:
  User id           : 16040
  User name         : test1
  Domain-name       : default
  User MAC          : 00e0-4c97-31f6
  User IP address   : -
  User IPv6 address : -
  User access time  : 2009/02/15 19:10:52
  User accounting session ID : huawei25525500000000f****2016040
  Option82 information : -
  User access type  : 802.1x

AAA:
  User authentication type : 802.1x authentication
  Current authentication method : RADIUS
  Current authorization method : -
  Current accounting method : RADIUS
```

当用户使用Telnet方式登录设备时，输入用户名**test**和密码**YsHsjx_202206**后，在设备上可以通过**display access-user domain**和**display access-user user-id**命令查看用户所属的域和接入类型。

```
<Router> display access-user domain default_admin
-----
UserID Username      IP address      MAC             Status
-----
16009 test           10.135.18.217  -               Success
-----
Total: 1, printed: 1
<Router> display access-user user-id 16009
Basic:
  User id           : 16009
```

```
User name          : test
Domain-name        : default_admin
User MAC           : -
User IP address    : 10.135.18.217
User IPv6 address  : -
User access time   : 2009/02/15 05:10:52
User accounting session ID : huawei25525500000000f****2016009
Option82 information : -
User access type   : Telnet
```

AAA:

```
User authentication type : Administrator authentication
Current authentication method : Local
Current authorization method : Local
Current accounting method : None
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10 to 11
#
authentication-profile name p1
dot1x-access-profile d1
authentication mode multi-authen max-user 100
#
radius-server template rd1
radius-server shared-key cipher %^%#Q75cNQ6IF(e#L4WMxP~-%^7'u17,]D87GO{"[o]`D%^%#
radius-server authentication 192.168.2.30 1812 weight 80
radius-server accounting 192.168.2.30 1813 weight 80
radius-server retransmit 2
#
aaa
authentication-scheme abc
authentication-mode radius
authentication-scheme auth
authorization-scheme autho
accounting-scheme abc
accounting-mode radius
domain default
authentication-scheme abc
accounting-scheme abc
radius-server rd1
domain default_admin
authentication-scheme auth
authorization-scheme autho
local-user test password irreversible-cipher $1a$KQje%lp2q/$bBk."}ISO@KQje%lp2q/$bBk."}ISO@$
local-user test privilege level 3
local-user test service-type telnet
#
interface Vlanif11
ip address 192.168.2.29 255.255.255.0
#
interface Ethernet2/0/0
port link-type access
port default vlan 10
authentication-profile p1
#
interface Ethernet2/0/1
port link-type access
port default vlan 11
#
telnet server enable #
user-interface vty 0 14
```

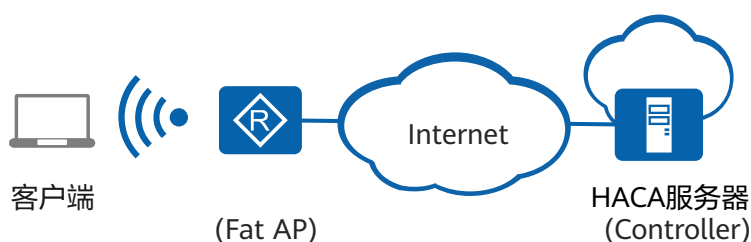
```
authentication-mode aaa
#
dot1x-access-profile name d1
#
return
```

1.12.4 配置采用 HACA 协议进行认证和计费示例

组网需求

某企业采用Router对接入互联网的用户进行管理，将Controller服务器作为HACA服务器，部署在云端实现外置Portal服务器以及认证、计费服务器的功能。接入用户通过Router到云端中的HACA服务器进行认证、计费，减少企业的日常网络维护成本。

图 1-32 采用 HACA 协议进行认证、计费组网图



配置思路

采用如下的思路配置采用HACA协议对用户进行认证、计费。

1. 配置HACA服务器模板。
2. 配置认证方案、计费方案。
3. 在域下应用HACA服务器模板和认证方案、计费方案。

说明

请确保Router与HACA服务器路由可达。

操作步骤

步骤1 配置HACA服务器模板

配置HACA服务器模板haca。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] haca-server template haca
```

配置HACA服务器IP地址、端口。

```
[Router-haca-haca] haca-server server-address 10.1.1.1 50300 default
```

使能HACA功能。

```
[Router-haca-haca] haca enable
[Router-haca-haca] quit
```

步骤2 配置认证方案、计费方案

配置认证方案auth，认证模式为HACA认证。

```
[Router] aaa
[Router-aaa] authentication-scheme auth
[Router-aaa-authen-auth] authentication-mode haca
[Router-aaa-authen-auth] quit
```

配置计费方案acc，计费模式为HACA，并配置当开始计费失败时，允许用户上线。

```
[Router-aaa] accounting-scheme acc
[Router-aaa-accounting-acc] accounting-mode haca
[Router-aaa-accounting-acc] accounting start-fail online
```

配置实时计费间隔为3分钟。

```
[Router-aaa-accounting-acc] accounting realtime 3
[Router-aaa-accounting-acc] quit
```

步骤3 配置huawei域，在域下应用认证方案auth、计费方案acc、HACA服务器模板haca

```
[Router-aaa] domain huawei
[Router-aaa-domain-huawei] authentication-scheme auth
[Router-aaa-domain-huawei] accounting-scheme acc
[Router-aaa-domain-huawei] haca-server haca
[Router-aaa-domain-huawei] quit
[Router-aaa] quit
```

步骤4 检查配置结果

在Router上执行命令**display haca-server configuration template template-name**，可以观察到该HACA服务器模板的配置与要求一致。

```
[Router] display haca-server configuration template haca
-----
HACA-server template name           : haca
HACA-server server-ip-address(port) : 10.1.1.1(50300)
HACA-server pki-realm-name          : default
HACA-server Status                   : INIT
HACA-server source-ip-address       : -
HACA-server down-delay-interval(sec) : 30
HACA-server response-timeout-interval(sec) : 5
HACA-server domain-included         : ORIGINAL
HACA-server heart-beat-interval(min) : 20
HACA-server reconnection-interval(min) : 1
HACA-server user-syn-interval(min)   : 9
HACA-server server-escape-state      : 2
HACA-server accounting-stop-packet resend : 0
-----
Total 1,1 printed
```

同时在Router上执行命令**display domain**，可以观察到该域的配置与要求一致。

```
[Router] display haca-server configuration template haca
-----
Domain-name           : huawei
Domain-index          : 4
Domain-state          : Active
Authentication-scheme-name : auth
Accounting-scheme-name  : acc
Authorization-scheme-name : -
Service-scheme-name    : -
RADIUS-server-template : default
Accounting-copy-RADIUS-template : -
HWTACACS-server-template : -
HACA-server-template   : haca
User-group             : -
-----
```



```
Push-url-address      :-
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
haca-server template haca
haca-server server-address 10.1.1.1 50300 default
haca enable
haca-server accounting-stop-packet resend 0
#
aaa
authentication-scheme auth
authentication-mode haca
accounting-scheme acc
accounting-mode haca
accounting realtime 3
accounting start-fail online
domain huawei
authentication-scheme auth
accounting-scheme acc
haca-server haca
#
return
```

1.13 AAA FAQ

1.13.1 为什么在使用 AAA 认证方式时，管理员用户不能使用不认证

为提高设备的安全性，不允许管理用户以不认证的方式在AAA认证通过。

1.13.2 RADIUS 模板下的配置正确且 AAA 的认证方式为 RADIUS，RADIUS 服务器用户配置正确，为什么认证总是失败

出现此情况一般原因有以下可能：

- 在服务器侧没有配置客户端IP地址，RADIUS服务器不回应认证报文。
- 设备与RADIUS服务器配置的共享密钥不一致。

1.13.3 为什么 RADIUS 动态授权总是出现服务器检查失败

因为未在设备配置正确的RADIUS授权服务器。

1.13.4 TACACS 模板下的配置正确且 AAA 的认证方式为 HWTACACS，TACACS 服务器用户配置正确，为什么认证总是失败

出现此情况一般原因有以下可能：

- 在服务器侧没有配置客户端IP地址，TACACS服务器不回应认证报文。

- 设备与TACACS服务器配置的共享密钥不一致。

1.13.5 在设备上执行命令时，为什么总会在 TACACS 服务器收到计费报文

因为在设备上配置了命令行记录功能。如果要取消此功能，在AAA视图下执行`undo cmd recording-scheme`命令。

1.13.6 display access-user 时，为何有时不能显示 802.1x 用户的 IP 地址

用户认证上线后，设备捕获该用户的ARP报文，并从中学习到用户的IP地址。如果用户没有发出ARP报文，那么设备上就无法学习、并显示用户的IP地址。

1.13.7 RADIUS 动态下发 ACL 需要哪几个属性

属性号	类型	属性值	是否标准属性	说明
31	string	用户MAC地址	是	-
11	string	ACL number	是	这两个属性可任选其一
82	string	ACL描述	否，是华为私有属性	

1.13.8 RADIUS 动态下发 VLAN 需要哪几个属性

属性号	类型	属性值	是否标准属性
31	string	用户MAC地址	是
64	integer	13	是
65	integer	6	是
81	string	VLAN ID	是

1.13.9 配置 HWTACACS 有哪些限制

HWTACACS模板如果有用户在使用、被域绑定或被停止计费报文使用，不允许删除。

如果服务器有报文在发送，不允许修改服务器IP地址。

1.13.10 设备支持 RADIUS 配置用户的级别吗，如何实现

设备支持通过RADIUS配置用户的级别，与AAA本地认证时配置本地用户的级别效果一样。

需要在RADIUS服务器上进行相关配置。

1.13.11 为什么在 Radius 服务器上配置用户级别是 1 级，但是用户登录后能使用超过级别超过 1 级的命令

请使用命令**display current-configuration**检查设备上的配置，查看是否使用了**command-privilege level**命令改变了命令行的级别。

1.13.12 AR 替换 ME60 设备后，如何转换 RADIUS 属性实现对接？

AR替换ME60设备后，AR设备和ME60设备的某些RADIUS属性需要转换，才能正确对接RADIUS服务器。

例如，AR设备和ME60设备华为私有属性有如下对应关系：

- AR设备的RADIUS私有属性中的1号属性HW-Input-Peak-Information-Rate对应ME60设备中的RADIUS私有属性3号属性。
- AR设备的RADIUS私有属性中的3号属性HW-Input-Committed-Burst-Size对应ME60设备中的RADIUS私有属性1号属性。

根据上述对应关系，在AR设备上将1号私有属性转换为3号私有属性，3号私有属性转换为1号私有属性：

- 在RADIUS服务器模板视图下，执行命令**radius-server attribute translate**启动RADIUS属性转换功能。
- 在RADIUS服务器模板视图下，执行命令**radius-attribute translate HW-Input-Peak-Information-Rate HW-Input-Committed-Burst-Size receive**将接收报文中的1号私有属性转换成3号私有属性。
- 在RADIUS服务器模板视图下，执行命令**radius-attribute translate HW-Input-Committed-Burst-Size HW-Input-Peak-Information-Rate receive**将接收报文中的3号私有属性转换成1号私有属性。

当AR设备接收到RADIUS服务器发送的报文且报文中包含1号私有属性或者3号私有属性时，AR设备就可以正确获取属性信息。

其它属性对应关系，比如AR设备的RADIUS私有属性中的4号属性HW-Output-Peak-Information-Rate对应ME60设备中的RADIUS私有属性6号属性（具体对应关系可参见AR设备手册中的RADIUS属性表和ME60设备手册中的RADIUS属性表），可按照类似的方法设置属性转换。

2 DAA 配置

- [2.1 DAA简介](#)
- [2.2 DAA原理描述](#)
- [2.3 DAA应用场景](#)
- [2.4 DAA配置任务概览](#)
- [2.5 DAA配置注意事项](#)
- [2.6 DAA缺省配置](#)
- [2.7 配置DAA](#)
- [2.8 DAA配置举例](#)

2.1 DAA 简介

定义

目的地址计费DAA（Destination Address Accounting），是一种根据用户访问的目的地址进行精细化流量计费的技术。

目的

在校园网等可运营网络场景中，一般情况下，当用户访问内网资源时，运营商不收费；而当用户访问外网资源时，运营商需要收取一定费用。

通过DAA技术，可以在园区内网、外网分离控制的基础上，按照目的地址区分不同的业务类型并实施不同的流量统计和计费策略，最终实现基于业务的精细化运营计费功能。

2.2 DAA 原理描述

基本概念

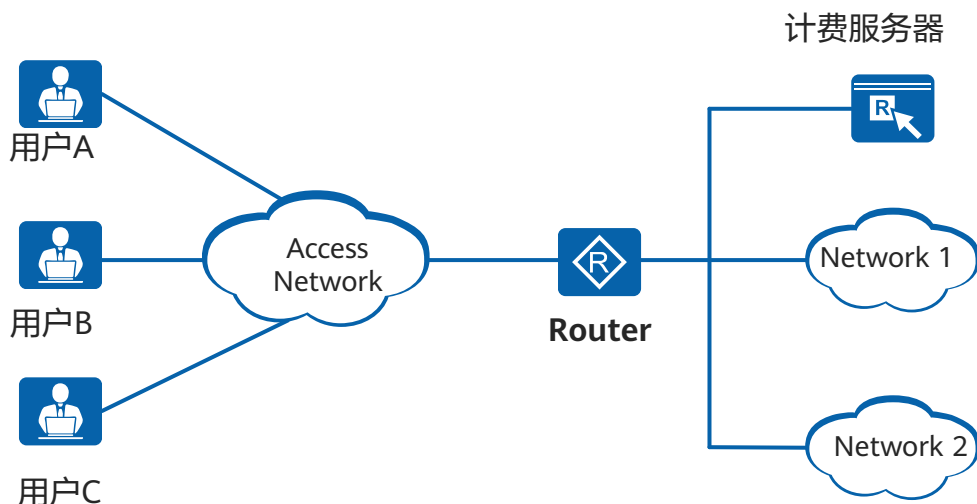
- 流量识别：按照用户访问的目的IP地址对流量进行分类。

- 费率级别：用来标识特定目的地址的数据流，目的是使设备可以根据费率级别来实现不同的流量统计或计费策略。
- 流量组：将识别出的流量与费率级别进行关联。

实现机制

DAA业务基本组网模型如图2-1所示，Router和计费服务器配合完成按照目的地址进行计费的功能。

图 2-1 DAA 业务基本组网模型图



对于一次用户认证上网过程，DAA业务的处理流程如下：

说明

本流程省略用户进行认证的过程，假设已经认证成功。

1. 用户正常上网并产生流量。
2. 当用户访问Network1和Network2时，设备解析出流量中的目的地址，通过ACL流量规则来进行流量识别。
3. 识别出流量后，设备获取ACL对应的费率级别，将流量映射到指定的费率级别。
4. 设备按照费率级别对用户的流量信息进行统计。
5. （可选）设备每隔一定的时间向计费服务器发送实时计费报文，并在此报文中携带每个费率级别对应的流量统计信息。
6. （可选）计费服务器接收到实时计费报文后，解析出报文中每个费率级别的流量信息，按照一定的计费规则进行实时计费。
7. 用户下线时，设备向计费服务器发送计费结束报文，此报文中携带用户此次上网每个费率级别的全部流量信息。
8. 计费服务器接收到计费结束报文后，解析出报文中每个费率级别在此次上网过程中的所有流量信息，按照一定的计费规则进行计费。

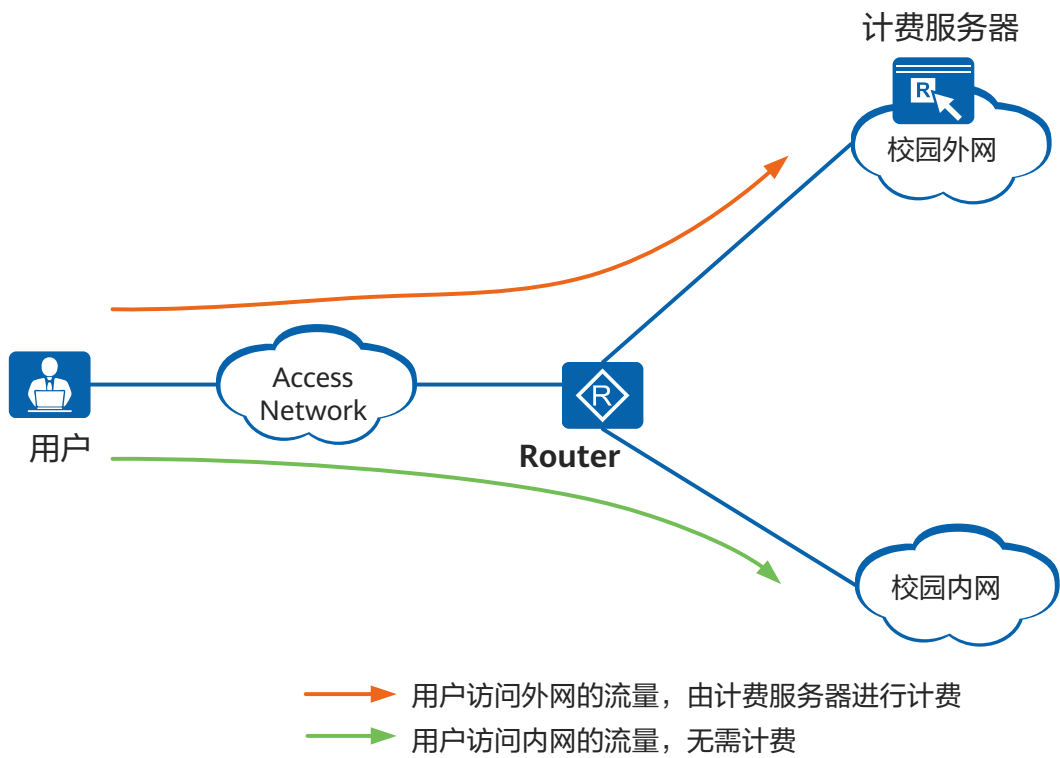
9. 用户上网过程结束。

2.3 DAA 应用场景

如图2-2所示，校园网用户可以通过Router访问校园内网或校园外网的各种资源。内网由学校自主建设，包含有大量的学习资源，用户可以免费访问；外网由学校租用运营商网络，需要按照流量向运营商支付相应费用。

配置DAA后，对于用户访问校园外网的流量，设备会统计流量信息并将该信息上报给计费服务器，由服务器进行计费；对于用户访问校园内网的流量，设备不需要将流量信息上报给计费服务器。

图 2-2 通过 DAA 实现对用户访问内外网资源的分开计费



2.4 DAA 配置任务概览

DAA的配置任务如表2-1所示。

表 2-1 DAA 配置任务概览

场景	描述	对应任务
对用户访问特定目的地址的流量进行计费	当管理员由于特殊原因需要对用户访问特定目标网络的流量进行计费时，可以通过流量识别规则将需要计费的流量识别出来并对其进行流量统计。此后，设备将统计后的信息发送给计费服务器，从而实现按照目的地址进行计费的功能。	1. 2.7.1 配置流量识别规则 2. 2.7.2 配置流量的费率级别 3. 2.7.3 配置流量计费
对用户访问外部网络的所有流量进行计费	在校园网等可运营网络场景中，一般情况下，当用户访问内网资源时，运营商不收费；而当用户访问外网资源时，运营商需要收取一定费用。 此时，由于用户对外网的需求灵活多样，无法准确统计用户访问的目的网段，而内网目的网段较少且相对固定。可以通过流量识别规则将用户访问内网的流量识别出来不进行统计，同时将设备统计到的其他所有的非内网流量信息发送给计费服务器，实现内网不计费、外网计费的功能。	1. 2.7.1 配置流量识别规则 2. 2.7.2 配置流量的费率级别 3. 2.7.3 配置流量计费 4. 在AAA域下执行 statistic enable（AAA域视图） 命令使能域用户的流量统计，对除了指定费率级别流量外的其他所有流量信息进行统计。

2.5 DAA 配置注意事项

涉及网元

表 2-2 本特性涉及网元

角色	产品	说明
AAA服务器	华为公司或第三方公司的AAA服务器产品。	负责对用户进行认证、计费和授权。
Portal服务器	华为公司或第三方公司的Portal服务器产品。	负责接收Portal客户端认证请求的服务器端系统，提供免费门户服务和基于Web认证的界面，与接入设备交互认证客户端的认证信息。 仅外置Portal认证方式需要该网元。

License 支持

DAA是设备的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

2.6 DAA 缺省配置

DAA的缺省配置如表2-3所示。

表 2-3 DAA 缺省配置

参数	缺省值
流量的识别规则	未配置
流量的费率级别	未配置
指定费率级别流量的流量统计功能	未使能
指定费率级别流量的计费功能	未使能

2.7 配置 DAA

前置任务

DAA提供了一种根据用户目的地址进行精细化流量计费的方案，但是仅仅依靠DAA不足以实现该方案。因此，需要首先完成以下配置任务：

- 配置用户的接入认证方式为Portal或PPPoE。
具体配置请参见3.5 配置NAC或PPPoE配置。

说明

DAA仅支持Portal或PPPoE认证。并且使用Portal认证时，认证必须配置在路由主接口上。

- 配置用户通过RADIUS方式进行认证和计费。
具体配置请参见AAA配置中的配置采用RADIUS方式进行认证、授权和计费。

2.7.1 配置流量识别规则

背景信息

要想针对用户访问不同目标网络的流量实施不同的计费策略，首先要识别出访问不同目标网络的流量，即需要通过配置访问控制列表ACL（Access Control List）来进行流量识别。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置流量识别规则

1. 执行命令**acl [number] acl-number [match-order { auto | config }]**，使用编号创建一个数字型的高级ACL，并进入高级ACL视图；或者执行命令**acl name acl-name { advance | acl-number } [match-order { auto | config }]**，使用名称创建一个命名型的高级ACL，进入高级ACL视图。

缺省情况下，未创建ACL。

2. 执行命令**rule [rule-id] permit ip { source { source-ip-address { source-wildcard | src-netmask } | any } | destination { destination-ip-address { destination-wildcard | des-netmask } | any } }**，创建高级ACL规则。

缺省情况下，未创建ACL规则。

说明

高级ACL编号的取值范围是3000～3999。

为无线用户配置或修改的ACL（3000～3031），需要执行命令**commit**下发到AP才能生效。

目的地址信息为必选配置，源地址信息为可选配置。同时配置源地址和目的地址信息，可以更加精确的指定需要进行计费的流量。

如果用户指定了所有目的地址、源地址（即配置了上面步骤中的**any**参数），则该流量识别规则无效。

----结束

2.7.2 配置流量的费率级别

背景信息

识别出用户访问不同目的网络的流量后，设备需要通过流量组，将流量与费率级别进行关联，为后期根据费率级别采用不同的流量统计和计费策略提供基础。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**traffic-group group-name**，创建一个流量组并进入流量组视图。

缺省情况下，未创建任何流量组。

步骤3 执行命令**acl acl-number tariff-level tariff-level**，配置流量的费率级别。

缺省情况下，未配置流量的费率级别。

说明

- 一个流量组下最多可以为8条ACL指定费率级别。
- 设备支持为不同的流量指定相同的费率级别。
- 如果存在同时配置源地址和目的地址的ACL规则，并且其目的地址与其他ACL规则的目的地址重复，配置时建议将这种ACL规则匹配数值较小的费率级别（*tariff-level*）。例如，网络中大多数访问目的地址A的用户采用相同的费率、对应ACL3000；少数源地址是B、访问目的地址A的用户采用另一个费率、对应ACL3001，此时，ACL3001对应的费率级别应当小于ACL3000对应的费率级别。

步骤4 执行命令**quit**，返回系统视图。

步骤5 执行命令**traffic-group group-name enable**，全局应用流量组。

缺省情况下，全局下没有应用任何流量组。

说明

执行本步骤应用流量组后，如果用户对该流量组进行了以下更改，则只有重新执行本步骤，修改后的配置才会生效。

- 通过命令**acl tariff-level**更改了流量的费率级别。
- 通过命令**rule（高级ACL视图）**更改了流量识别规则中的源地址或目的地址。

----结束

2.7.3 配置流量计费

背景信息

所谓流量计费就是在认证用户的设备上统计用户上网期间产生的流量，并将统计结果发送给计费服务器，由计费服务器根据统计结果进行计费。计费服务器可以对已通过802.1X、MAC、Portal或PPPoE认证的上网用户按照流量统计结果进行计费。

完成流量的识别规则和费率级别的配置后，设备已通过费率级别将来自不同目的地址的流量进行了标识。然后，在QoS模板中配置流量监管和流量统计功能，来控制流量的带宽和统计流量信息。由于费率级别能够标识流量的目的地址，为指定的费率级别绑定相应的QoS模板后，设备就可以控制发往指定目的地址的流量带宽，并可以统计发往指定目的地址的流量信息；使能了计费功能后，设备会将统计到的流量信息发送给计费服务器，由计费服务器进行计费。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**qos-profile profile-name**，创建一个QoS模板并进入QoS模板视图。

缺省情况下，未配置任何QoS模板。

步骤3 （可选）执行命令**car cir cir-value [pir pir-value] [cbs cbs-value pbs pbs-value] { inbound | outbound }**，在QoS模板中配置流量监管。

缺省情况下，QoS模板中没有配置流量监管。

用户如果希望限制流量的带宽，则要求配置此步骤。

步骤4 执行命令**statistics enable**，在QoS模板中使能流量统计功能。

缺省情况下，QoS模板中的流量统计功能未使能。

步骤5 执行命令**quit**，返回系统视图。

步骤6 执行命令**aaa**，进入AAA视图。

步骤7 执行命令**domain domain-name**，进入域视图。

缺省情况下，设备存在两个域：“default”和“default_admin”。“default”用于普通接入用户的域，“default_admin”用于管理员的域。

步骤8 执行命令**tariff-level tariff-level { qos-profile profile-name | accounting-on } ***，配置费率级别绑定的QoS模板和计费功能。

缺省情况下，未配置费率级别绑定的QoS模板和计费功能。

----结束

2.7.4 检查配置结果

背景信息

完成DAA的所有配置后，可通过命令查看配置结果。

操作步骤

- 执行命令**display traffic-group { all | name group-name }**，查看流量组信息。
- 执行命令**display domain [name domain-name]**，查看费率级别绑定的QoS模板和计费功能是否开启。

----结束

2.8 DAA 配置举例

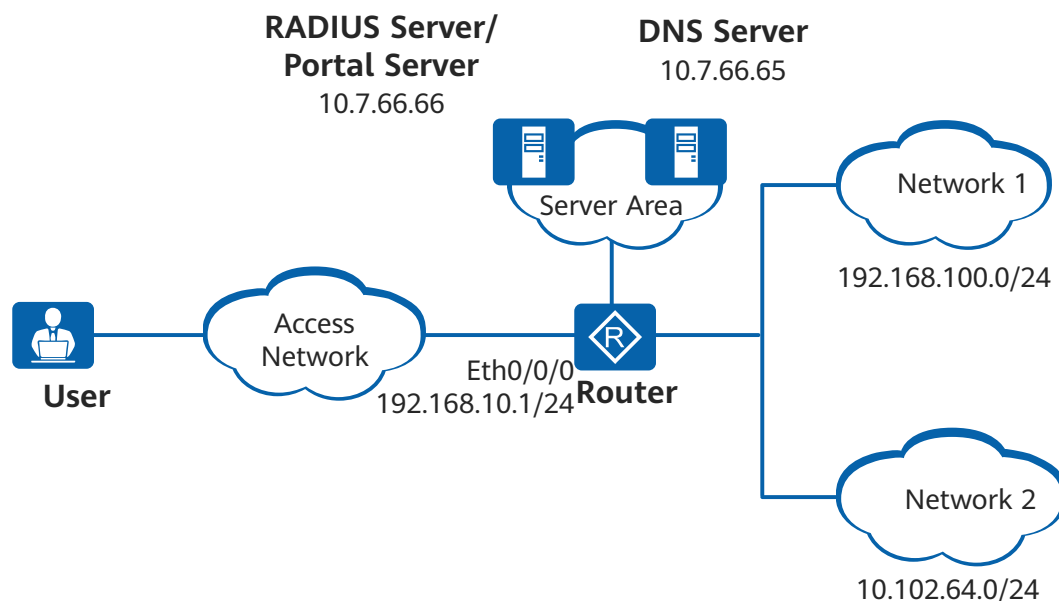
2.8.1 配置对指定网络进行计费示例

组网需求

如图2-3所示，校园网内Portal用户通过Router访问校园网络Network1（192.168.100.0/24）和Network2（10.102.64.0/24）的各种资源。Network1为免费资源，Network2需要按照流量收取相应费用。

此时，可以在Router上部署DAA功能，当用户访问Network1时，不收取费用；但当用户访问Network2时，会按照访问的流量来收取费用。

图 2-3 配置对指定网络进行计费组网图



配置思路

采用如下的思路配置DAA示例：

1. 创建VLAN并配置接口允许通过的VLAN，保证网络通畅。
2. 创建并配置RADIUS服务器模板、AAA方案以及域，并在域下绑定RADIUS服务器模板与AAA方案，保证设备与RADIUS服务器之间的信息交互。
3. 配置Portal认证，使用户终端能够通过Portal认证方式接入网络。
4. 配置DAA，根据用户访问的目的地址进行计费。
 - a. 配置流量识别规则，针对两个不同网段，按照用户访问的目的地址的不同对流量进行分类。
 - b. 配置流量的费率级别，为去往两个不同网段的流量指定不同的费率级别。其中，去往Network1流量的费率级别为1，去往Network2流量的费率级别为2。
 - c. 根据费率级别分别配置流量的计费策略：
 - 对于费率级别1，统计流量但不计费。
 - 对于费率级别2，统计流量并且计费。

说明

请确保RADIUS服务器模板内的RADIUS服务器的地址、端口号和共享密钥配置正确，并且和RADIUS服务器保持一致。

请确保Router与服务器路由可达，用户与Network1和Network2之间路由可达。

操作步骤

步骤1 配置与用户连接的接口Eth0/0/0

```
<Huawei> system-view
[Huawei] sysname Router
[Router] interface ethernet 0/0/0
[Router-Ethernet0/0/0] undo portswitch
[Router-Ethernet0/0/0] ip address 192.168.10.1 24
[Router-Ethernet0/0/0] quit
```

步骤2 配置AAA

配置RADIUS服务器模板shiva。RADIUS认证服务器的IP地址是10.7.66.66，端口为1812；RADIUS计费服务器的IP地址为10.7.66.66，端口为1813；共享密钥为YsHsjx_202206。

```
[Router] radius-server template shiva
[Router-radius-shiva] radius-server authentication 10.7.66.66 1812
[Router-radius-shiva] radius-server accounting 10.7.66.66 1813
[Router-radius-shiva] radius-server shared-key cipher YsHsjx_202206
[Router-radius-shiva] quit
```

配置认证方案auth，认证模式为RADIUS认证。

```
[Router] aaa
[Router-aaa] authentication-scheme auth
[Router-aaa-authen-auth] authentication-mode radius
[Router-aaa-authen-auth] quit
```

配置计费方案abc，计费模式为RADIUS计费。

```
[Router-aaa] accounting-scheme abc
[Router-aaa-accounting-abc] accounting-mode radius
[Router-aaa-accounting-abc] quit
```

配置AAA域huawei，在域下应用认证方案auth、计费方案abc和RADIUS模板shiva。

```
[Router-aaa] domain huawei
[Router-aaa-domain-huawei] authentication-scheme auth
[Router-aaa-domain-huawei] accounting-scheme abc
[Router-aaa-domain-huawei] radius-server shiva
[Router-aaa-domain-huawei] quit
[Router-aaa] quit
```

步骤3 配置DAA

配置流量的识别规则ACL规则3000和ACL规则3001。

```
[Router] acl 3000
[Router-acl-adv-3000] rule 1 permit ip destination 192.168.100.0 0.0.0.255
[Router-acl-adv-3000] quit
[Router] acl 3001
[Router-acl-adv-3001] rule 1 permit ip destination 10.102.64.0 0.0.0.255
[Router-acl-adv-3001] quit
```

配置流量的费率级别。其中，访问目的网络192.168.100.0/24的流量费率级别为1，访问目的网络10.102.64.0/24的流量费率级别为2。

```
[Router] traffic-group huawei
[Router-traffic-group-huawei] acl 3000 tariff-level 1
[Router-traffic-group-huawei] acl 3001 tariff-level 2
[Router-traffic-group-huawei] quit
[Router] traffic-group huawei enable
```

配置流量计费。

```
[Router] qos-profile huawei
[Router-qos-profile-huawei] statistics enable
[Router-qos-profile-huawei] quit
[Router] aaa
[Router-aaa] domain huawei
[Router-aaa-domain-huawei] tariff-level 1 qos-profile huawei
```

```
[Router-aaa-domain-huawei] tariff-level 2 qos-profile huawei accounting-on
[Router-aaa-domain-huawei] quit
[Router-aaa] quit
```

步骤4 配置Portal认证

```
# 配置Portal服务器模板“abc”。
[Router] web-auth-server abc
[Router-web-auth-server-abc] server-ip 10.7.66.66
[Router-web-auth-server-abc] port 50200
[Router-web-auth-server-abc] url http://10.7.66.66:8080/webagent
[Router-web-auth-server-abc] shared-key cipher YsHsjx_202206
[Router-web-auth-server-abc] quit

# 配置Portal接入模板“web1”。
[Router] portal-access-profile name web1
[Router-portal-access-profile-web1] web-auth-server abc layer3
[Router-portal-access-profile-web1] quit

# 配置免认证规则模板“default_free_rule”，放通到DNS服务器的报文。
[Router] free-rule-template name default_free_rule
[Router-free-rule-default_free_rule] free-rule 1 destination ip 10.7.66.65 mask 32
[Router-free-rule-default_free_rule] quit

# 配置认证模板“p1”，并在其上绑定Portal接入模板“web1”、指定认证模板下用户的
# 强制认证域为“huawei”、绑定免认证规则模板为“default_free_rule”。

[Router] authentication-profile name p1
[Router-authen-profile-p1] portal-access-profile web1
[Router-authen-profile-p1] access-domain huawei force
[Router-authen-profile-p1] free-rule-template default_free_rule
[Router-authen-profile-p1] quit

# 在接口Eth0/0/0上绑定认证模板“p1”，使能Portal认证。

[Router] interface ethernet 0/0/0
[Router-Ethernet0/0/0] authentication-profile p1
[Router-Ethernet0/0/0] quit
```

步骤5 验证配置结果

执行命令**display traffic-group name group-name**，查看流量组huawei中的信息。

```
[Router] display traffic-group name huawei
```

Acl-id	Tariff-level

3000	1
3001	2

Total: 2	

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
authentication-profile name p1
portal-access-profile web1
free-rule-template default_free_rule
access-domain huawei force
#
```

```
radius-server template shiva
radius-server shared-key cipher %^%#}O.80;*E;-a|55;)dmDEL;b!0YmhAPafqkV{CMf;%^%#
radius-server authentication 10.7.66.66 1812 weight 80
radius-server accounting 10.7.66.66 1813 weight 80
#
acl number 3000
rule 1 permit ip destination 192.168.100.0 0.0.0.255
acl number 3001
rule 1 permit ip destination 10.102.64.0 0.0.0.255
#
qos-profile huawei
statistics enable
#
free-rule-template name default_free_rule
free-rule 1 destination ip 10.7.66.65 mask 255.255.255.255
#
web-auth-server abc
server-ip 10.7.66.66
port 50200
shared-key cipher %^%#'=oP;*.KKUSPqB7M5Cf2G)!!t/&,$!!!!!!!!!!%^%#
url http://10.7.66.66:8080/webagent
#
portal-access-profile name web1
web-auth-server abc layer3
#
aaa
authentication-scheme auth
authentication-mode radius
accounting-scheme abc
accounting-mode radius
domain huawei
authentication-scheme auth
accounting-scheme abc
radius-server shiva
tariff-level 1 qos-profile huawei
tariff-level 2 qos-profile huawei accounting-on
statistic enable
#
interface Ethernet0/0/0
undo portswitch
ip address 192.168.10.1 255.255.255.0
authentication-profile p1
#
traffic-group huawei
acl 3000 tariff-level 1
acl 3001 tariff-level 2
traffic-group huawei enable
#
return
```

3 NAC 配置

背景信息

说明

NAC功能主要用于用户认证和控制用户的网络访问权限，可能涉及使用个人用户某些通信内容。建议您只有在所适用法律法规允许的目的和范围内方可启用相应的功能。在使用、存储用户通信内容的过程中，您应采取足够的措施以确保用户的通信内容受到严格保护。

[3.1 NAC原理描述](#)

[3.2 NAC应用场景](#)

[3.3 NAC配置注意事项](#)

[3.4 NAC缺省配置](#)

[3.5 配置NAC](#)

[3.6 维护NAC](#)

[3.7 NAC配置举例](#)

[3.8 NAC FAQ](#)

3.1 NAC 原理描述

3.1.1 NAC 概述

简介

NAC（Network Access Control）称为网络接入控制，通过对接入网络的客户端和用户的认证保证网络的安全，是一种“端到端”的安全技术。

三种认证方式比较

NAC包括三种认证方式：802.1X认证、MAC认证和Portal认证。由于三种认证方式认证原理不同，各自适合的场景也有所差异，实际应用中，可以根据场景部署某一种合适的认证方式，也可以部署几种认证方式组成的混合认证，混合认证的组合方式以设备实际支持为准。三种认证方式比较如[表3-1](#)所示。

表 3-1 认证方式对比

对比项	802.1X认证	MAC认证	Portal认证
适合场景	新建网络、用户集中、信息安全要求严格的场景	打印机、传真机等哑终端接入认证的场景	用户分散、用户流动性大的场景
客户端需求	需要	不需要	不需要
优点	安全性高	无需安装客户端	部署灵活
缺点	部署不灵活	需登记MAC地址，管理复杂	安全性不高

NAC 与 AAA

NAC与AAA互相配合，共同完成接入认证功能。

- NAC：用于用户和接入设备之间的交互。NAC负责控制用户的接入方式，即用户采用802.1X，MAC或Portal中的哪一种方式接入，接入过程中的各类参数和定时器。确保合法用户和接入设备建立安全稳定的连接。
- AAA：用于接入设备与认证服务器之间的交互。AAA服务器通过对接入用户进行认证、授权和计费实现对接入用户访问权限的控制。

3.1.2 802.1X 认证原理描述

3.1.2.1 802.1X 认证简介

定义

802.1X协议是一种基于端口的网络接入控制协议（Port based network access control protocol）。“基于端口的网络接入控制”是指在局域网接入设备的端口这一级验证用户身份并控制其访问权限。

优点

- 802.1X协议为二层协议，不需要到达三层，对接入设备的整体性能要求不高，可以有效降低建网成本。
- 认证报文和数据报文通过逻辑接口分离，提高安全性。

802.1X 认证系统

如图3-1所示，802.1X系统为典型的Client/Server结构，包括三个实体：客户端、接入设备和认证服务器。

图 3-1 802.1X 认证系统



- 客户端一般为一个用户终端设备，用户可以通过启动客户端软件发起802.1X认证。客户端必须支持局域网上的可扩展认证协议EAPoL（Extensible Authentication Protocol over LANs）。
- 接入设备通常为支持802.1X协议的网络设备，它为客户端提供接入局域网的端口，该端口可以是物理端口，也可以是逻辑端口。
- 认证服务器用于实现对用户进行认证、授权和计费，通常为RADIUS服务器。

3.1.2.2 802.1X 认证协议

简介

802.1X认证系统使用可扩展认证协议EAP（Extensible Authentication Protocol）来实现客户端、设备端和认证服务器之间的信息交互。EAP协议可以运行在各种底层，包括数据链路层和上层协议（如UDP、TCP等），而不需要IP地址。因此使用EAP协议的802.1X认证具有良好的灵活性。

- 在客户端与设备端之间，EAP协议报文使用EAPoL（EAP over LANs）封装格式，直接承载于LAN环境中。
- 在设备端与认证服务器之间，用户可以根据客户端支持情况和网络安全要求来决定采用的认证方式。
 - EAP终结方式中，EAP报文在设备端终结并重新封装到RADIUS报文中，利用标准RADIUS协议完成认证、授权和计费。
 - EAP中继方式中，EAP报文被直接封装到RADIUS报文中（EAP over RADIUS，简称为EAPoR），以便穿越复杂的网络到达认证服务器。

EAP 报文

图 3-2 EAP 报文

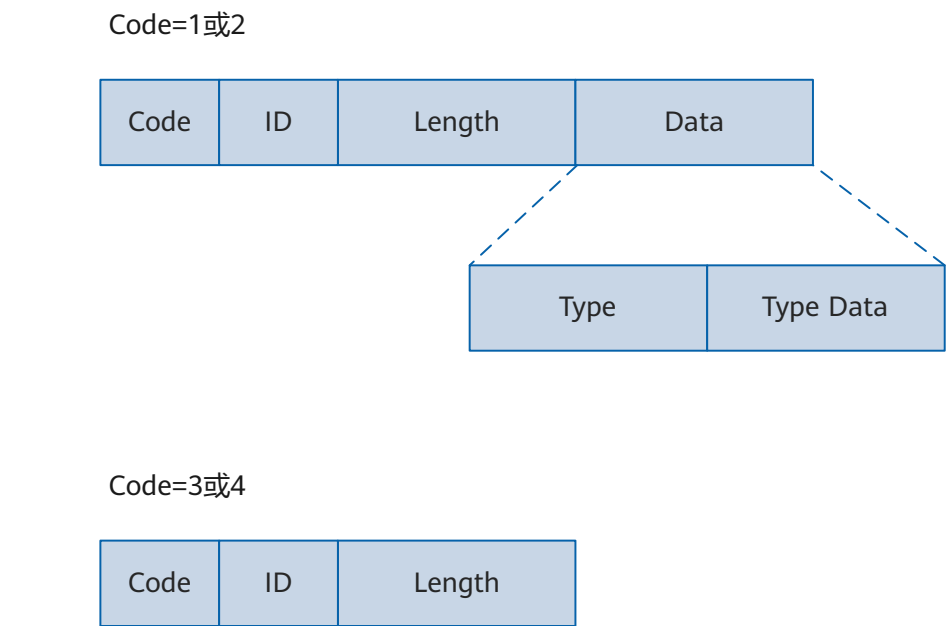


表 3-2 EAP 报文字段解释

字段	字节数	含义
Code	1	表示EAP数据包的类型，共有以下几种 1（Request）：请求。 2（Response）：响应。 3（Success）：成功。 4（Failure）：失败。
ID	1	用于匹配Request和Response。
Length	2	表示EAP数据包的长度，包括Code、ID、Length以及Data各字段。超出Length域范围的字节应该视为数据链路层填充，在接收时应该被忽略掉。

字段	字节数	含义
Data	0或多个字节	Data字段的格式由Code的值来决定。 - 当Code取值为1或者2时，EAP为Request和Response报文，Data包含Type、Type Data两个字段，如上图所示。其中，Type为一个字节，表示Request或Response的类型。Type Data为多个字节，内容由Type字段的值决定。 - 当Code取值为3或者4时，EAP为Success和Failure报文，没有Data字段。

表 3-3 Type 常用取值

Type字段值	类型	含义
1	Identity	要求客户端发送用户输入的用户名信息。
2	Notification	非必须的通知消息，传送一些警告消息，例如密码已过期、帐号被锁等。
3	NAK	仅用于Response帧，表示否定确认。例如设备用了客户端不支持的认证方法发起请求，客户端可利用Response/NAK消息以告知设备其支持的认证方法。
4	MD5-Challenge	认证方法为MD5质询法。
5	OTP（One-Time Password）	认证方法为一次性密码，例如网银付费时系统会通过短信发送一个一次性密码。
6	GTC（Generic Token Card）	认证方法为通用令牌卡。跟OTP类似，只不过GTC往往对应一个实际的设备，例如许多国内银行都会给申请网银的用户一个动态令牌，这个令牌就是GTC。
13	EAP-TLS	认证方法为EAP-TLS。
21	EAP-TTLS	认证方法为EAP-TTLS。
25	EAP-PEAP	认证方法为EAP-PEAP。
254	Expanded Types	扩展类型，支持厂商自定义的类型。
255	Experimental use	实验新的类型时做测试用的类型。

EAPoL

EAPoL是802.1X协议定义的一种报文封装格式，主要用于在客户端和设备之间传送EAP协议报文，以允许EAP协议报文在LAN上传送。其报文结构如下：

图 3-3 EAPoL 报文

PAE Ethernet Type	Protocol Version	Type	Length	Packet Body
-------------------	------------------	------	--------	-------------

表 3-4 EAPoL 报文字段解释

字段	字节数	含义
PAE Ethernet Type	2	表示协议类型，值为0x888E。
Protocol Version	1	表示EAPoL帧的发送方所支持的协议版本号。 0x01：802.1X-2001。 0x02：802.1X-2004。 0x03：802.1X-2010。
Type	1	表示EAPoL数据帧类型，有四种取值： 00：EAP-Packet，认证报文数据，用于承载认证信息。 01：EAPoL-Start，认证开始报文，用于用户主动发起认证过程。 02：EAPoL-Logoff，下线请求报文，用于用户主动发起下线请求。 03：EAPoL-Key，密钥信息报文。 EAPoL-Start，EAPoL-Logoff和EAPoL-Key仅在客户端和设备端之间存在。
Length	2	表示数据长度，也就是Packet Body字段的长度，单位为字节。如果为0，则表示没有后面的Packet Body字段。EAPoL-Start和EAPoL-Logoff报文的Length值都为0。
Packet Body	取决于报文内容	表示数据内容。

EAPoR

为支持EAP中继方式，RADIUS协议增加了两个属性：EAP-Message（EAP消息）和Message-Authenticator（消息认证码）。其中，EAP-Message属性用来封装EAP报

文，Message-Authenticator属性用于对认证报文进行认证和校验，防止非法报文欺骗。其报文结构如下：

图 3-4 EAPoR 报文

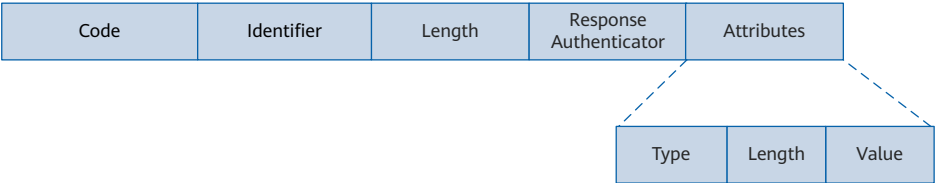


表 3-5 EAPoR 报文字段解释

字段	字节数	含义
Code	1	表示RADIUS报文的类型。
Identifier	1	用来匹配请求报文和响应报文，以及检测在一段时间内重发的请求报文。客户端发送请求报文后，服务器返回的响应报文中的Identifier值应与请求报文中的Identifier值相同。
Length	2	指定RADIUS报文的长度。超过Length取值的字节将作为填充字符而忽略。如果接收到的报文的实际长度小于Length的取值，则该报文会被丢弃。
Response Authenticator	16	验证RADIUS服务器的响应报文，同时还用于用户密码的加密。
Attributes	长度不确定	Attribute为报文的内容主体，用来携带专门的认证、授权和计费信息，提供请求和响应报文的配置细节。Attribute可以包括多个属性，每一个属性都采用（Type、Length、Value）三元组的结构来表示。 • 类型（Type），1个字节，取值为1～255，用于表示属性的类型。 • 长度（Length），表示该属性（包括类型、长度和属性值）的长度，单位为字节。 • 属性值（Value），表示该属性的信息，其格式和内容由类型和长度决定，最大长度为253字节。

认证方式选择

- EAP中继方式的优点是设备端处理更简单，支持更多的认证方法，缺点则是认证服务器必须支持EAP，且处理能力要足够强。对于常用的EAP-TLS、EAP-TTLS、EAP-PEAP三种认证方式，EAP-TLS需要在客户端和服务端上加载证书，安全性最高，EAP-TTLS、EAP-PEAP需要在服务端上加载证书，但不需要在客户端加载证书，部署相对灵活，安全性较EAP-TLS低。
- EAP终结方式的优点是现有的RADIUS服务器基本均支持PAP和CHAP认证，无需升级服务器，但设备端的工作比较繁重，因为在这种认证方式中，设备端不仅要来自客户端的EAP报文中提取客户端认证信息，还要通过标准的RADIUS协议对这

些信息进行封装，且不能支持除MD5-Challenge之外的其它EAP认证方法。PAP与CHAP的主要区别是CHAP密码通过密文方式传输，而PAP密码通过明文的方式传输。因而PAP方式认证的安全性较低，实际应用通常采用CHAP方式认证。

3.1.2.3 802.1X 认证流程

802.1X 认证的触发方式

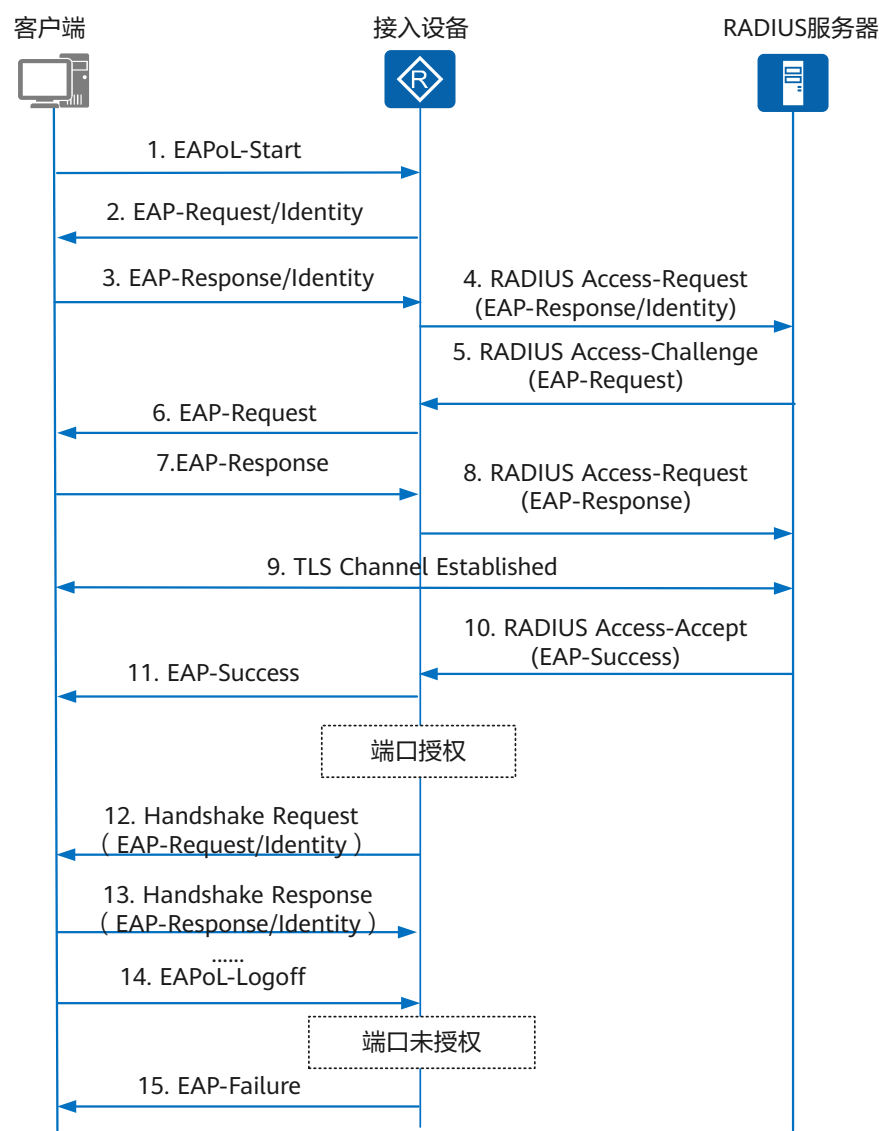
802.1X认证有以下触发方式：

- 客户端发送EAPoL-Start报文触发认证。
- 客户端发送DHCP/ARP或任意报文触发认证。
- 设备以组播形式发送EAP-Request/Identity报文触发认证。

EAP 中继和 EAP 终结的认证流程

802.1X系统支持EAP中继方式和EAP终结方式与远端RADIUS服务器交互完成认证。以客户端发送EAPoL-Start报文触发认证为例，EAP中继方式和EAP终结方式的802.1X认证流程分别如[图3-5](#)与[图3-6](#)所示。

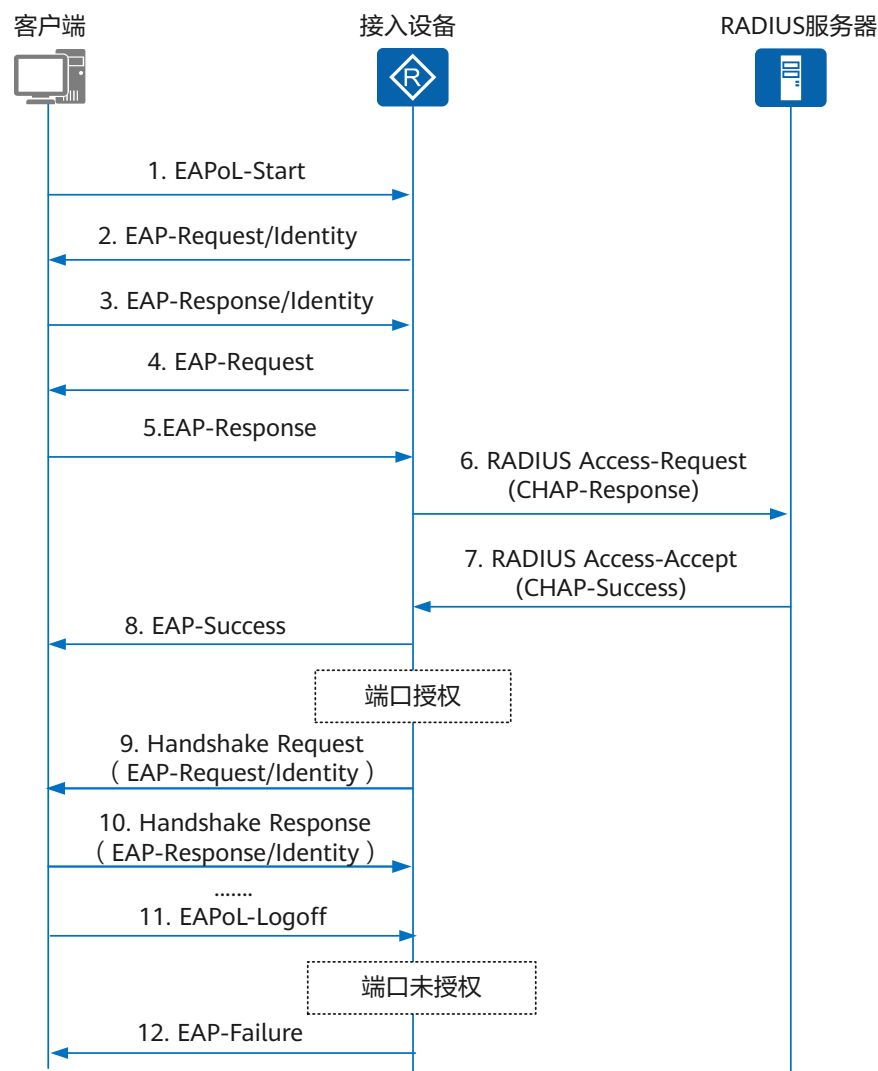
图 3-5 EAP 中继认证流程



1. 客户端发送EAPoL-Start报文触发认证。
2. 设备端发出一个Identity类型的请求报文（EAP-Request/Identity）请求客户端的身份信息。
3. 客户端程序响应设备端发出的请求，将身份信息通过Identity类型的响应报文（EAP-Response/Identity）发送给设备端。
4. 设备端响应报文中的EAP报文封装在RADIUS报文（RADIUS Access-Request）中，发送给认证服务器进行处理。
5. RADIUS服务器收到设备端转发的身份信息后，启动和客户端EAP认证方法的协商。RADIUS服务器选择一个EAP认证方法，将认证方法封装在RADIUS Access-Challenge报文中，发送给设备端。
6. 设备端收到RADIUS服务器发送的RADIUS Access-Challenge报文后，将其中的EAP信息转发给客户端。
7. 客户端收到由设备端传来的EAP信息后，解析其中的EAP认证方法，如果支持该认证方法，客户端发送EAP-Response报文给设备端；如果不支持，客户端选择一个支持的EAP认证方法封装到EAP-Response报文中发送给设备端。

8. 设备将报文中的EAP信息封装到RADIUS报文中发给RADIUS服务器。
9. RADIUS服务器收到后，如果客户端与服务器选择的认证方法一致，EAP认证方法协商成功，开始认证。以EAP-PEAP认证方法为例，服务器将自己的证书封装到RADIUS报文中发送给设备端。设备收到后将证书转发给客户端。客户端校验服务器证书（可选），与RADIUS服务器协商TLS参数，建立TLS隧道。TLS隧道建立完成后，用户信息将通过TLS加密在客户端、设备端和RADIUS服务器之间传输。如果客户端与服务器的EAP认证方法协商失败，则终止认证流程，通知设备认证失败，设备去关联客户端。
10. RADIUS服务器完成对客户端身份验证之后，通知设备认证成功。
11. 设备收到认证通过报文后向客户端发送认证成功报文（EAP-Success），并将端口改为授权状态，允许用户通过该端口访问网络。
12. 用户在线期间，设备端会通过向客户端定期发送握手报文的方法，对用户的在线情况进行监测。
13. 客户端收到握手报文后，向设备发送应答报文，表示用户仍然在线。缺省情况下，若设备端发送的两次握手请求报文都未得到客户端应答，设备端就会让用户下线，防止用户因为异常原因下线而设备无法感知。
14. 客户端可以发送EAPoL-Logoff报文给设备端，主动要求下线。
15. 设备端把端口状态从授权状态改变成未授权状态，并向客户端发送EAP-Failure报文。

图 3-6 EAP 终结认证流程



EAP终结方式与EAP中继方式的认证流程相比，不同之处在于EAP认证方法协商由客户端和设备端完成，之后设备端会把用户信息送给RADIUS服务器，进行相关的认证处理。而在EAP中继方式中，EAP认证方法协商由客户端和服务器完成，设备端只是负责将EAP报文封装在RADIUS报文中透传认证服务器，整个认证处理都由认证服务器来完成。

3.1.2.4 802.1X 授权

认证用于确认尝试接入网络的用户身份是否合法，而授权则用于指定身份合法的用户所能拥有的网络访问权限，即用户能够访问哪些资源。授权最基础也是最常用的授权参数是VLAN、ACL和UCL组，此处以RADIUS授权进行说明，其他授权方式的授权方法以及更多可授权的参数请参见[AAA授权方案](#)。

VLAN

为了将受限的网络资源与未认证用户隔离，通常将受限的网络资源和未认证的用户划分到不同的VLAN。用户认证成功后，认证服务器将指定VLAN授权给用户。此时，设备会将用户所属的VLAN修改为授权的VLAN，授权的VLAN并不改变接口的配置。但是，授权的VLAN优先级高于用户配置的VLAN，即用户认证成功后生效的VLAN是授权

的VLAN，用户配置的VLAN在用户下线后生效。RADIUS服务器授权VLAN时，必须同时使用以下RADIUS标准属性：

- **Tunnel-Type**：必须配置为13
- **Tunnel-Medium-Type**：必须配置为6
- **Tunnel-Private-Group-ID**：可以是VLAN ID、VLAN描述、VLAN名称和VLAN pool

用户组

用户组指具有相同角色、相同权限等属性的一组用户（终端）的集合。每个用户组可以关联不同的ACL、CAR、用户VLAN、报文优先级，因而通过用户组授权，可以实现对每类用户进行基于ACL的访问控制、基于VLAN的访问控制、流量控制以及优先级控制，管理更灵活。

比如，由于ACL资源有限，当每用户需要的授权ACL较多时，上线授权的用户数无法达到规格，但实际用户数很大，用户权限的分类比较少的，此时可以使用用户组，每一组用户复用ACL，以利用有限的ACL支持较大规格的用户进行ACL授权。用户组可以在RADIUS服务器上配置，也可以在设备端配置（需在AAA域下应用）。如果用户希望使用RADIUS服务器下发的用户组授权，需要保证RADIUS服务器上下发的用户组在设备上已经配置（不需在AAA域下应用）。

RADIUS服务器下发用户组授权的方式和下发ACL ID的方式一样，都是用11号标准属性Filter-Id来携带，属性值填充用户组名称。11号属性将优先被当成ACL编号处理。当设备上不存在该ACL编号的时候，则当成用户组处理，如果设备上也不存在该用户组时，则授权失败。

RADIUS服务器下发的用户组授权优先级高于设备端配置的用户组授权，当服务器下发的用户组授权失败后，用户会采用设备端配置的用户组授权。

free-rule

用户认证成功之前，为满足用户基本的网络访问需求，需要用户认证成功前就能获取部分网络访问权限。可在free-rule模板中配置free-rule规则，满足用户的认证成功前的网络访问需求。

3.1.2.5 802.1X 重认证

802.1X 认证成功用户

若管理员在认证服务器上修改了某一用户的访问权限、授权属性等参数，此时如果用户已经在线，则需要及时对该用户进行重认证以确保用户的合法性。配置对在线802.1X用户进行重认证功能后，设备会把保存的在线用户的认证参数（用户上线后，设备上会保存该用户的认证信息）发送到认证服务器进行重认证，若认证服务器上用户的认证信息没有变化，则用户正常在线；若用户的认证信息已更改，则用户将会被下线，此后用户需要重新进行认证。802.1X认证成功用户重认证方式如表3-6所示。

表 3-6 802.1X 认证成功用户重认证方式

配置点	方式	配置命令
在接入设备侧配置	对802.1X认证成功用户进行周期性重认证。	dot1x reauthenticate dot1x timer reauthenticate-period <i>reauthenticate-period-value</i>
	手动对指定MAC地址进行单次重认证。	dot1x reauthenticate mac-address <i>mac-address</i>
在 RADIUS 服务器侧配置	对802.1X认证成功的用户下发 RADIUS标准属性 Session-Timeout 和 Termination-Action ，其中， Session-Timeout 属性值为用户在线时长定时器， Termination-Action 属性值为1表示对用户进行重认证。当用户在线时长达到 Session-Timeout 的属性值时，设备会对用户进行重认证。	无

异常认证状态下的用户

用户在预连接阶段或认证失败阶段，设备会记录用户表项信息，并能够为用户分配受限的网络访问权限。为使用户能够及时认证成功，获取正常的网络访问权限，设备根据用户表项对没有认证成功的用户进行重认证。

在用户表项老化时间到达之前，如果用户重认证没有成功，设备将删除对应的表项信息，并收回授予用户的网络访问权限；如果用户重认证成功，设备将用户加入到认证成功用户表项，并授予认证成功后的网络访问权限。该部分用户的重认证方式如表 3-7所示。

表 3-7 异常认证状态下的用户重认证方式

用户状态	配置命令
RADIUS服务器 Down	authentication event authen-server-up action re-authen ：配置当RADIUS服务器真正UP时对用户进行重认证。
认证失败	authentication timer re-authen authen-fail <i>re-authen-time</i> ：配置对认证失败用户进行周期性重认证。
预连接	authentication timer re-authen pre-authen <i>re-authen-time</i> ：配置对预连接用户进行周期性重认证。

3.1.2.6 802.1X 认证用户下线

当用户已下线，而接入设备和RADIUS服务器未感知到该用户已下线时，会产生以下问题：

1. RADIUS服务器仍会对该用户进行计费，造成误计费。
2. 存在非法用户仿冒合法用户IP地址和MAC地址接入网络的风险。
3. 已下线用户数量过多的情况下，还会占用设备用户规格，可能会导致其他用户无法接入网络。

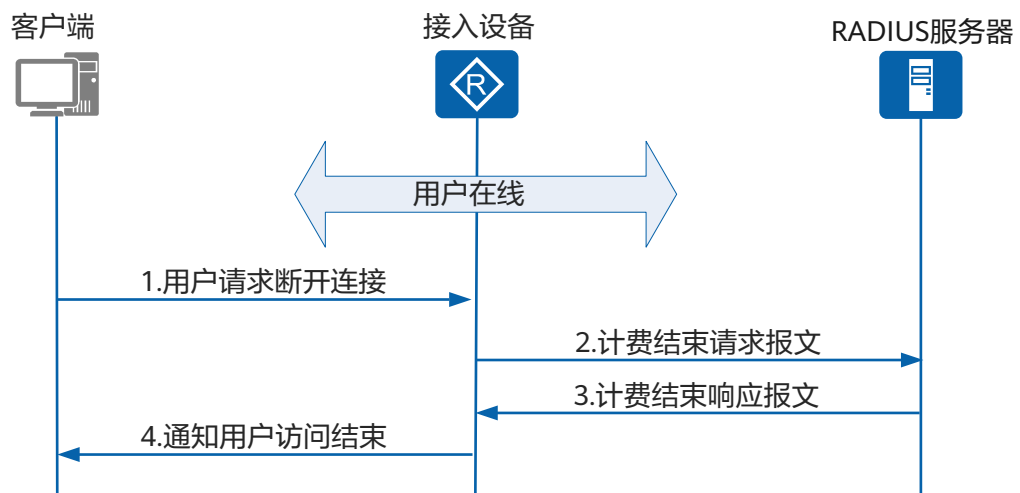
因此，接入设备要能够及时感知到用户已下线，删除该用户表项，并通知RADIUS服务器停止对该用户进行计费。

用户下线方式分为客户端主动下线，接入设备控制用户下线和服务器控制用户下线。

客户端主动下线

用户通过客户端软件发送EAPoL-Logoff报文主动下线，设备端会向客户端发一个EAP-Failure的报文，进而将端口状态由授权状态转换为非授权状态。

图 3-7 客户端主动下线的交互流程



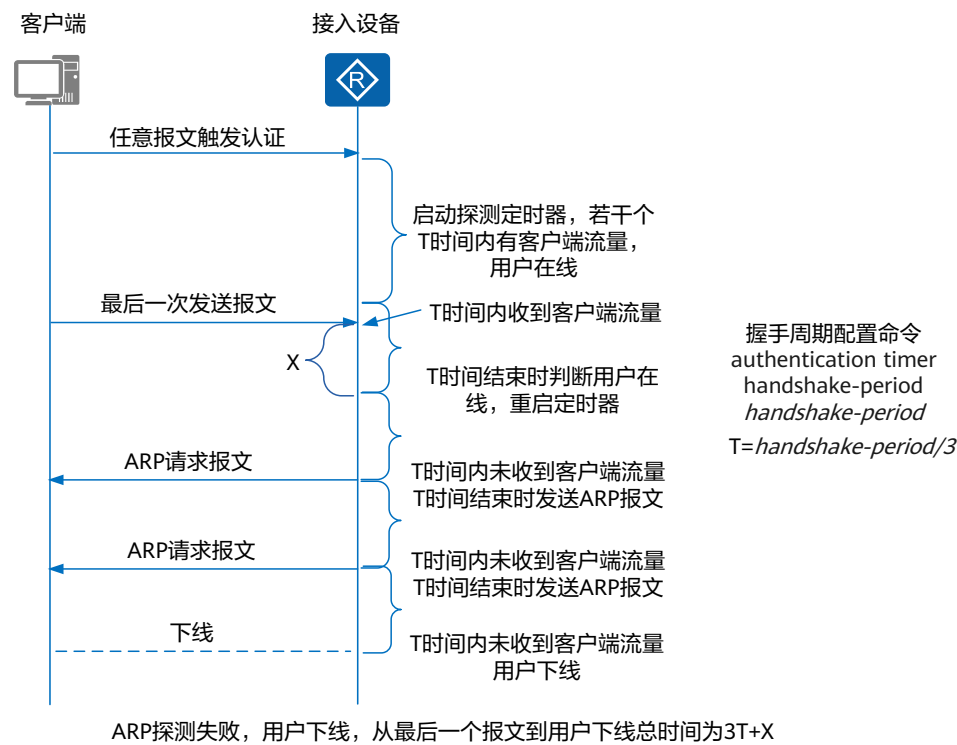
接入设备控制用户下线

接入设备控制用户下线有两种方式：

- 在接入设备上执行命令强制指定用户下线。
- 在接入设备上配置用户探测功能，用于探测用户是否在线。当用户在指定的时间内无响应，则认为用户下线，删除用户表项。

当管理员发现非法用户在线，或在测试中想让某一用户下线后重新上线，可以通过在设备上执行命令强制该用户下线。对于正常接入用户，会通过ARP探测对用户在线状态进行确认，如果探测到用户下线，则进行下线处理，删除用户表项。

图 3-8 用户下线探测流程



用户发送任意报文触发802.1X认证，同时启动探测定时器。假如握手周期为3T（通过命令**authentication timer handshake-period handshake-period**配置。 $T = \text{handshake-period} / 3$ ），则设备会在T、2T时刻进行用户探测，探测方式为ARP报文探测。以0～T时间段为例，T～2T与之类似，不再赘述。

- 如果在0～T时间段内，有用户流量经过设备，则在T时刻，设备认为用户在线，该时刻设备不会再发送探测报文，并重置探测定时器（即3T）周期。
- 如果在0～T时间段内，没有用户流量经过设备，则在T时刻，设备无法感知到用户是否在线，该时刻设备会发送探测报文。如果设备收到用户的回应报文，则认为用户在线，并重置探测定时器；如果未收到，则认为用户已下线。
- 如果在2T～3T时间段内，有用户流量经过设备，则在3T时刻，设备认为用户在线，该时刻设备重置探测定时器。
- 如果在2T～3T时间段内，没有用户流量经过设备，则在3T时刻，设备无法感知到用户是否在线，认为用户已下线。

如果在T、2T、3T时刻，设备均认为用户已下线，则设备会删除该用户的所有相关表项。为防止用户PC闲置时被异常下线，请不要将握手周期设置的过小，推荐使用默认值。

服务器控制用户下线

服务器控制用户下线有以下方式：

- RADIUS服务器可通过DM报文（ Disconnect Message ）强制用户下线。DM（ Disconnect Message ）是指用户离线报文，即由RADIUS服务器端主动发起的强制用户下线的报文。
- RADIUS服务器通过授权RADIUS标准属性Session-Timeout和Termination-Action。其中，Session-Timeout为用户在线时长定时器，Termination-Action属性值为0表示将用户下线。当用户在线的时长达到定时器指定的数值时，设备会将用户下线。

3.1.2.7 802.1X 定时器

802.1X认证中，通过定时器对认证过程进行控制，下面分别介绍一下这几种定时器。

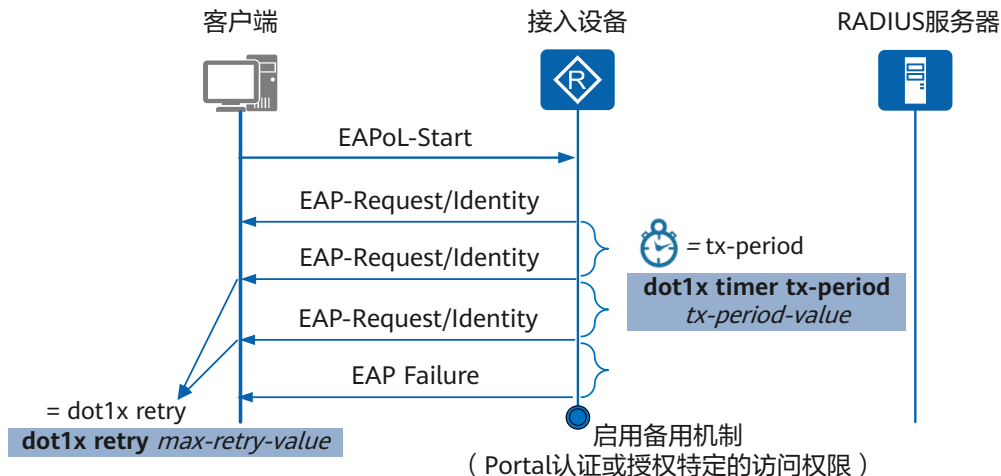
EAP-Request/Identity 请求超时

在802.1X认证中，设备会向客户端发送EAP-Request/Identity报文请求用户名，请求报文的重传次数和时间间隔由命令行控制。

如图3-9所示，设备发送EAP-Request/Identity请求报文超时后，向客户端发送认证失败报文。通常情况下，客户端认证失败时，为使得客户端能够继续访问网络，会在设备上启用备用机制（ Portal认证或授权特定访问权限 ）。

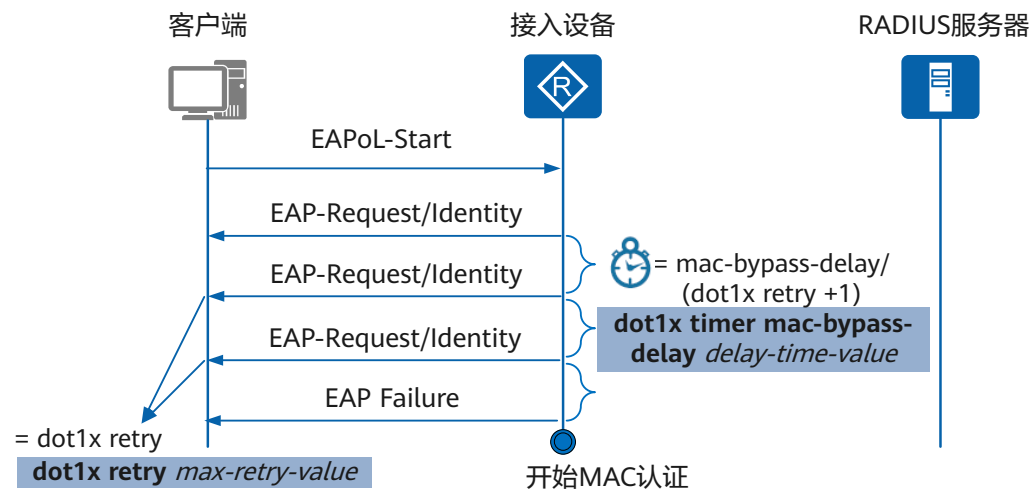
未配置MAC旁路认证时，定时器由命令**dot1x timer tx-period tx-period**配置，设备重传请求报文的次数通过命令**dot1x retry max-retry-value**配置。EAP-Request/Identity请求超时计算公式为： $\text{Timeout} = (\text{max-retry-value} + 1) * \text{tx-period-value}$

图 3-9 802.1X 认证 EAP-Request/Identity 请求超时



如图3-10所示，当配置MAC旁路认证功能后，设备首先会对用户进行802.1X认证，同时启动命令**dot1x timer mac-bypass-delay delay-time-value**配置的定时器。如果定时器时间 delay-time-value 到达而802.1X认证仍未成功，则设备开始对用户进行MAC认证。可以通过命令**dot1x retry max-retry-value**配置设备向802.1X用户发送认证请求的重传次数 max-retry-value ，重传时间间隔为 $\text{delay-time-value}/(\text{max-retry-value} + 1)$ 的整数部分。

图 3-10 MAC 旁路认证请求超时



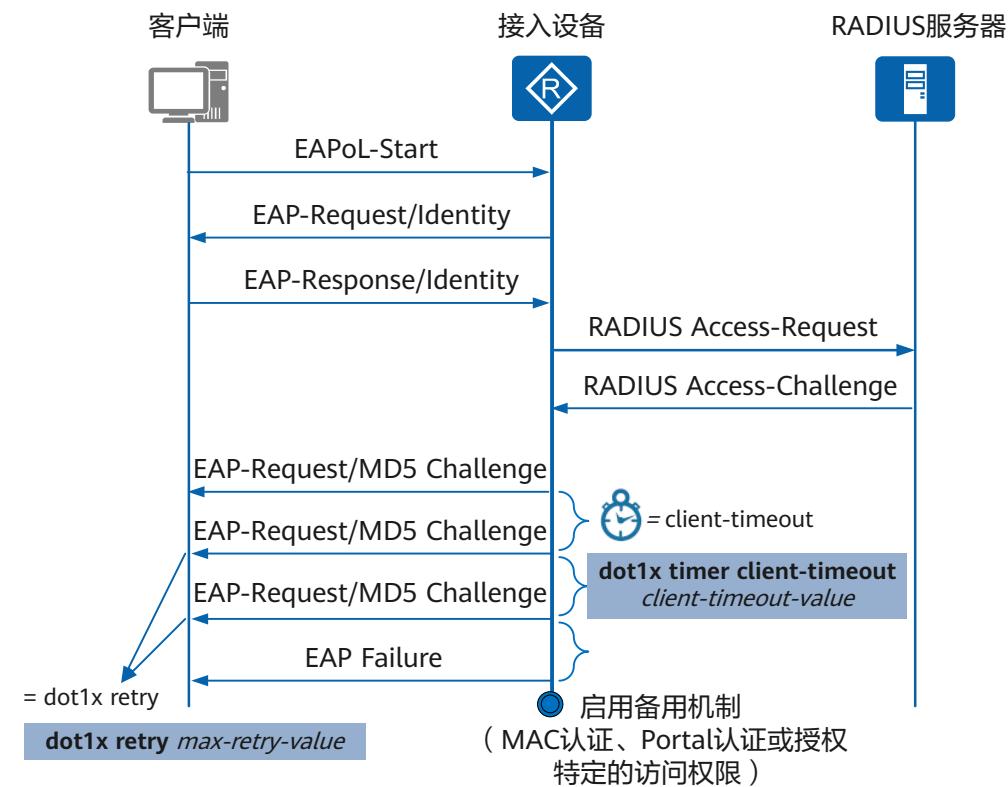
EAP-Request/MD5 Challenge 请求超时

当设备向802.1X客户端发送了EAP-Request/MD5 Challenge请求报文后，设备启动802.1X客户端认证超时定时器。若在该定时器设置的时长内，设备没有收到客户端的响应，则设备将重发该报文。若设备重传请求报文的次数达到配置的最大值（通过命令**dot1x retry max-retry-value**配置）后，仍然没有得到用户响应，则停止发送认证请求。这能够避免不断重复向用户发送认证请求报文而占用大量的设备资源。

如图3-11所示，设备发送EAP-Request/MD5 Challenge请求报文超时后，向客户端发送认证失败报文。通常情况下，客户端认证失败时，为使得客户端能够继续访问网络，会在接入设备上启用备用机制（MAC认证、Portal认证或授权特定的访问权限）。EAP-Request/MD5 Challenge请求超时计算公式如下所示：

$$\text{Timeout} = (\text{max-retry-value} + 1) * \text{client-timeout-value}$$

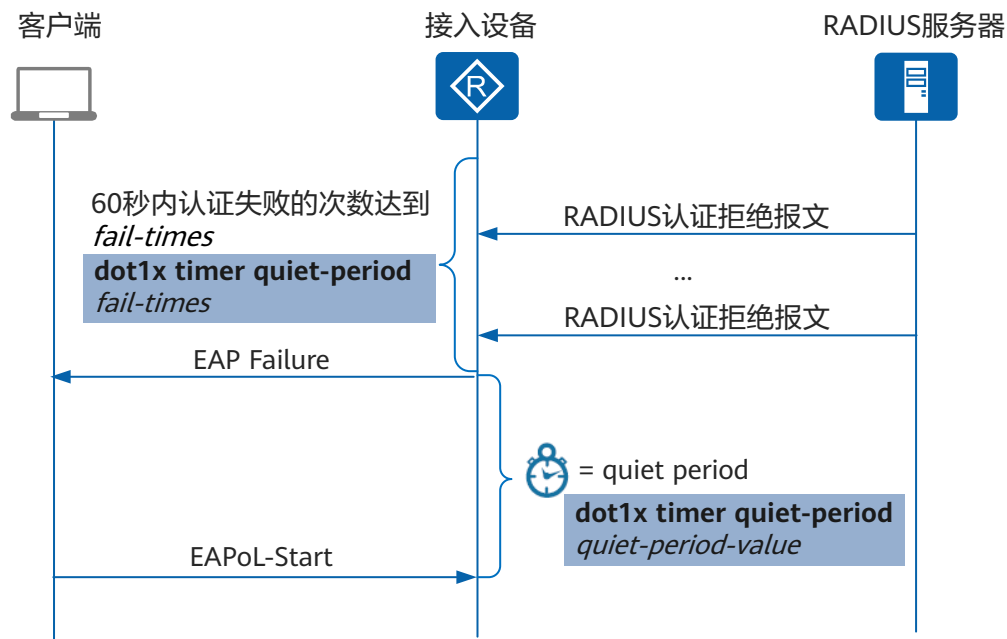
图 3-11 802.1X 认证 EAP-Request/MD5 Challenge 请求超时



802.1X 认证静默定时器

使能静默功能后，若某一用户在60秒内认证失败的次数超过命令**dot1x quiet-times fail-times**规定的值，则设备会将该用户静默一段时间，该时间由命令**dot1x timer quiet-period quiet-period-value**指定，在静默时间内，设备会丢弃该用户的802.1X认证请求，从而避免用户在短时间内频繁认证失败。

图 3-12 802.1X 认证静默定时器



3.1.3 MAC 认证原理描述

3.1.3.1 MAC 认证简介

定义

MAC认证，全称MAC地址认证，是一种基于接口和终端MAC地址对用户的访问权限进行控制的认证方法。

优点

- 用户终端不需要安装任何客户端软件。
- MAC认证过程中，不需要用户手动输入用户名和密码。
- 能够对不具备802.1X认证能力的终端进行认证，如打印机和传真机等哑终端。

认证系统

如图3-13所示，MAC认证系统为典型的客户端/服务器结构，包括三个实体：终端、接入设备和认证服务器。

图 3-13 MAC 认证系统



- 终端：尝试接入网络的终端设备。

- 接入设备：是终端访问网络的网络控制点，是企业安全策略的实施者，负责按照客户网络制定的安全策略，实施相应的准入控制（允许、拒绝、隔离或限制）。
- 认证服务器：用于确认尝试接入网络的终端身份是否合法，还可以指定身份合法的终端所能拥有的网络访问权限。

用户名形式

终端进行MAC认证时使用的用户名和密码需要在接入设备上预先配置，有以下几种形式。缺省情况下，终端进行MAC认证时使用的用户名和密码均为终端的MAC地址。

MAC认证时使用的用户名	密码	适用场景
终端的MAC地址	两种形式： 1. 终端的MAC地址 2. 指定的密码	客户端少量部署且MAC地址容易获取的场景，例如对少量接入网络的打印机进行认证。
指定的用户名	指定的密码	由于同一个接口下可以存在多个终端，此时所有终端均使用指定的用户名和密码进行MAC认证，服务器端仅需要配置一个账户即可满足所有终端的认证需求，适用于终端比较可信的网络环境。
DHCP选项，有三种形式： • circuit-id子选项 • remote-id子选项 • circuit-id子选项和remote-id子选项的组合	指定的密码	该场景下终端需通过DHCP方式获取IP地址，且需保证DHCP报文能够触发MAC认证。

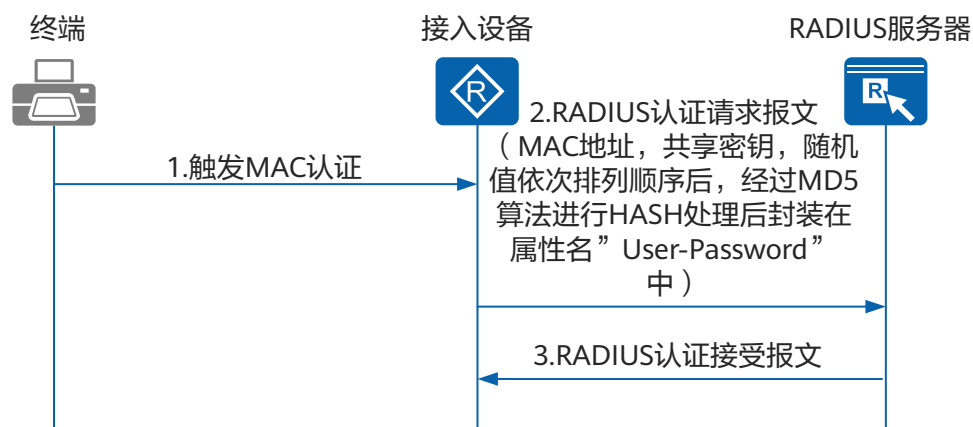
3.1.3.2 MAC 认证流程

对于MAC认证用户密码的处理，有PAP和CHAP两种方式：

- PAP：设备将MAC地址、共享密钥、随机值依次排列顺序后，经过MD5算法进行HASH处理后封装在属性名"User-Password"中。
- CHAP：设备将CHAP ID、MAC地址、随机值依次排列顺序后，经过MD5算法进行HASH处理后封装在属性名"CHAP-Password"和"CHAP-Challenge"中。

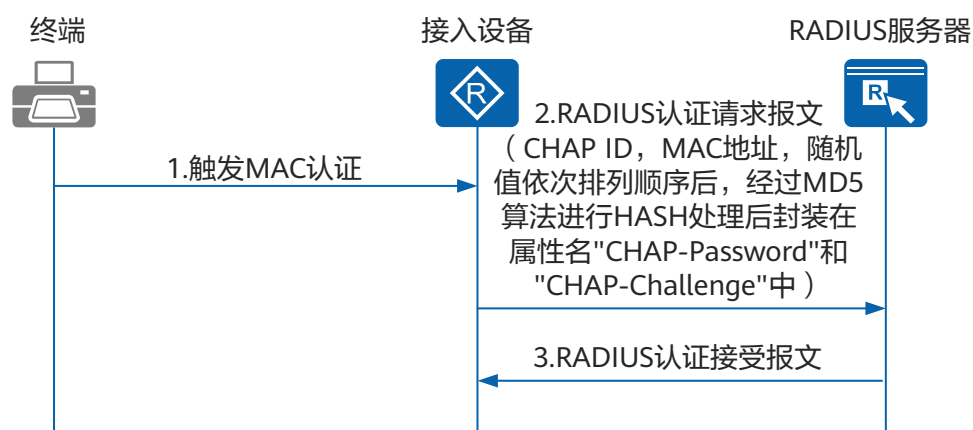
采用PAP和CHAP方式的MAC认证流程分别如[图3-14](#)和[图3-15](#)所示，两者实现方式相似，以下重点介绍PAP方式。

图 3-14 MAC 认证流程（PAP 方式）



1. 接入设备收到终端发送的arp/dhcp/dhcpv6/nd报文，触发MAC认证。
2. 设备随机生成一个随机值，并对MAC认证用户的MAC地址、共享密钥、随机值依次排列后经过MD5算法进行HASH处理，然后将用户名、HASH处理结果以及随机值封装在RADIUS认证请求报文中发送给RADIUS服务器，请求RADIUS服务器对该终端进行MAC认证。
3. RADIUS服务器使用收到的随机值对本地数据库中对应MAC认证用户进行MAC地址、共享密钥、随机值依次排列后经过MD5算法进行HASH处理，如果与设备发来的值相同，则向设备发送认证接受报文，表示终端MAC认证成功，允许该终端访问网络。

图 3-15 MAC 认证流程（CHAP 方式）



3.1.3.3 MAC 认证授权

认证用于确认尝试接入网络的用户身份是否合法，而授权则用于指定身份合法的用户所能拥有的网络访问权限，即用户能够访问哪些资源。授权最基础也是最常用的授权参数是VLAN、ACL和UCL组，此处以RADIUS授权进行说明，其他授权方式的授权方法以及更多可授权的参数请参见[AAA授权方案](#)。

VLAN

为了将受限的网络资源与未认证用户隔离，通常将受限的网络资源和未认证的用户划分到不同的VLAN。用户认证成功后，认证服务器将指定VLAN授权给用户。此时，设

设备会将用户所属的VLAN修改为授权的VLAN，授权的VLAN并不改变接口的配置。但是，授权的VLAN优先级高于用户配置的VLAN，即用户认证成功后生效的VLAN是授权的VLAN，用户配置的VLAN在用户下线后生效。RADIUS服务器授权VLAN时，必须同时使用以下RADIUS标准属性：

- **Tunnel-Type**：必须配置为13
- **Tunnel-Medium-Type**：必须配置为6
- **Tunnel-Private-Group-ID**：可以是VLAN ID、VLAN描述、VLAN名称和VLAN pool

用户组

用户组指具有相同角色、相同权限等属性的一组用户（终端）的集合。每个用户组可以关联不同的ACL、CAR、用户VLAN、报文优先级，因而通过用户组授权，可以实现对每类用户进行基于ACL的访问控制、基于VLAN的访问控制、流量控制以及优先级控制，管理更灵活。

比如，由于ACL资源有限，当每用户需要的授权ACL较多时，上线授权的用户数无法达到规格，但实际用户数很大，用户权限的分类比较少的，此时可以使用用户组，每一组用户复用ACL，以利用有限的ACL支持较大规格的用户进行ACL授权。用户组可以在RADIUS服务器上配置，也可以在设备端配置（需在AAA域下应用）。如果用户希望使用RADIUS服务器下发的用户组授权，需要保证RADIUS服务器上下发的用户组在设备上已经配置（不需在AAA域下应用）。

RADIUS服务器下发用户组授权的方式和下发ACL ID的方式一样，都是用11号标准属性Filter-Id来携带，属性值填充用户组名称。11号属性将优先被当成ACL编号处理。当设备上不存在该ACL编号的时候，则当成用户组处理，如果设备上也不存在该用户组时，则授权失败。

RADIUS服务器下发的用户组授权优先级高于设备端配置的用户组授权，当服务器下发的用户组授权失败后，用户会采用设备端配置的用户组授权。

free-rule

用户认证成功之前，为满足用户基本的网络访问需求，需要用户认证成功前就能获取部分网络访问权限。可在free-rule模板中配置free-rule规则，满足用户的认证成功前的网络访问需求。

3.1.3.4 MAC 认证重认证

MAC 认证成功用户

若管理员在认证服务器上修改了某一用户的访问权限、授权属性等参数，此时如果用户已经在线，则需要及时对该用户进行重认证以确保用户的合法性。MAC认证成功用户重认证方式如表3-8所示。

表 3-8 MAC 认证成功用户重认证方式

配置点	方式	配置命令
在接入设备侧配置	对MAC认证成功用户进行周期性重认证，从接入设备收到RADIUS认证接受报文开始计算， <i>reauthenticate-period-value</i> 时间之后，接入设备会重新请求RADIUS服务器对该终端进行MAC认证。	mac-authen reauthenticate mac-authen timer reauthenticate-period <i>reauthenticate-period-value</i>
	手动对指定MAC地址进行单次重认证。	mac-authen reauthenticate mac-address <i>mac-address</i>
在RADIUS服务器侧配置	对MAC认证成功的用户下发RADIUS标准属性 Session-Timeout 和 Termination-Action 。其中， Session-Timeout 属性值为用户在在线时长定时器， Termination-Action 属性值为1表示对用户进行重认证。当用户在线时长达到 Session-Timeout 的属性值时，设备会对用户进行重认证。	无

异常认证状态下的用户

从[3.1.7.2 MAC认证逻辑流程](#)章节可以看出，MAC认证时可能会存在RADIUS服务器Down或用户认证失败等异常状况。缺省情况下，异常认证状态下的用户将无任何网络访问权限。但一般情况下，会对其授予部分网络访问权限，如访问一些无关紧要的信息。当用户在线时间达到老化时间后，设备将删除用户表项，并收回授予用户的网络访问权限。为使这部分用户能够及时认证成功，获取正常的网络访问权限，设备可以对这些用户进行重认证。该部分用户的重认证方式如[表3-9](#)所示。

表 3-9 异常认证状态下的用户重认证方式

用户状态	配置命令
RADIUS服务器Down	authentication event authen-server-up action re-authen ：配置当RADIUS服务器真正UP时对用户进行重认证。
认证失败	authentication timer re-authen authen-fail <i>re-authen-time</i> ：配置对认证失败用户进行周期性重认证。
预连接	authentication timer re-authen pre-authen <i>re-authen-time</i> ：配置对预连接用户进行周期性重认证。

3.1.3.5 MAC 认证用户下线

当用户已下线，而接入设备和RADIUS服务器未感知到该用户已下线时，会产生以下问题：

1. RADIUS服务器仍会对该用户进行计费，造成误计费。

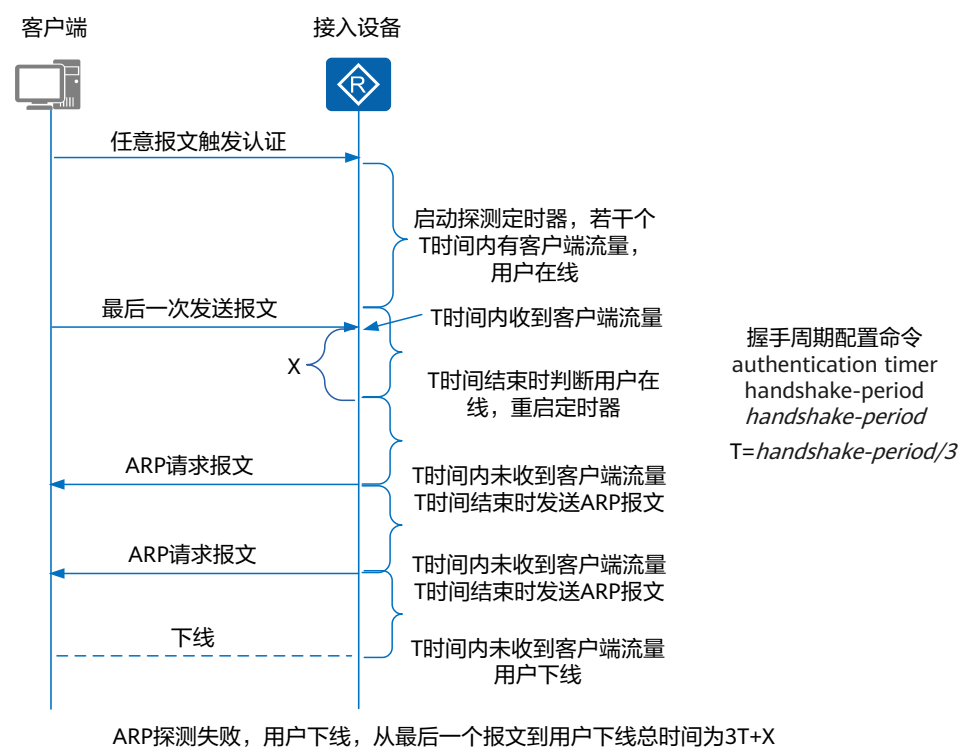
2. 存在非法用户仿冒合法用户IP地址和MAC地址接入网络的风险。

3. 已下线用户数量过多的情况下，还会占用设备用户规格，可能会导致其他用户无法接入网络。
- 因此，接入设备要能够及时感知到用户已下线，删除该用户表项，并通知RADIUS服务器停止对该用户进行计费。

接入设备控制用户下线

- 接入设备控制用户下线有两种方式：
- 在接入设备上执行命令cut access-user强制指定用户下线。
 - 在接入设备上配置用户探测功能，用于探测用户是否在线。当用户在指定的时间内无响应，则认为用户下线，删除用户表项。
- 当管理员发现非法用户在线，或在测试中想让某一用户下线后重新上线，可以通过在设备上执行命令强制该用户下线。对于正常接入用户，会通过ARP探测对用户在线状态进行确认，如果探测到用户下线，则进行下线处理，删除用户表项。

图 3-16 用户下线探测流程



- 假如握手周期为3T（通过命令authentication timer handshake-period handshake-period配置。T=handshake-period/3），则设备会在T、2T时刻进行用户探测，探测方式为ARP报文探测。以0～T时间段为例，T～2T与之类似，不再赘述。
- 如果在0～T时间段内，有用户流量经过设备，则在T时刻，设备认为用户在线，该时刻设备不会再发送探测报文，并重置探测定时器（即3T）周期。

- 如果在0~T时间段内，没有用户流量经过设备，则在T时刻，设备无法感知到用户是否在线，该时刻设备会发送探测报文。如果设备收到用户的回应报文，则认为用户在线，并重置探测定时器；如果未收到，则认为用户已下线。
- 如果在2T~3T时间段内，有用户流量经过设备，则在3T时刻，设备认为用户在线，该时刻设备重置探测定时器。
- 如果在2T~3T时间段内，没有用户流量经过设备，则在3T时刻，设备无法感知到用户是否在线，认为用户已下线。

如果在T、2T、3T时刻，设备均认为用户已下线，则设备会删除该用户的所有相关表项。为防止用户PC闲置时被异常下线，请不要将握手周期设置的过小，推荐使用默认值。

服务器控制用户下线

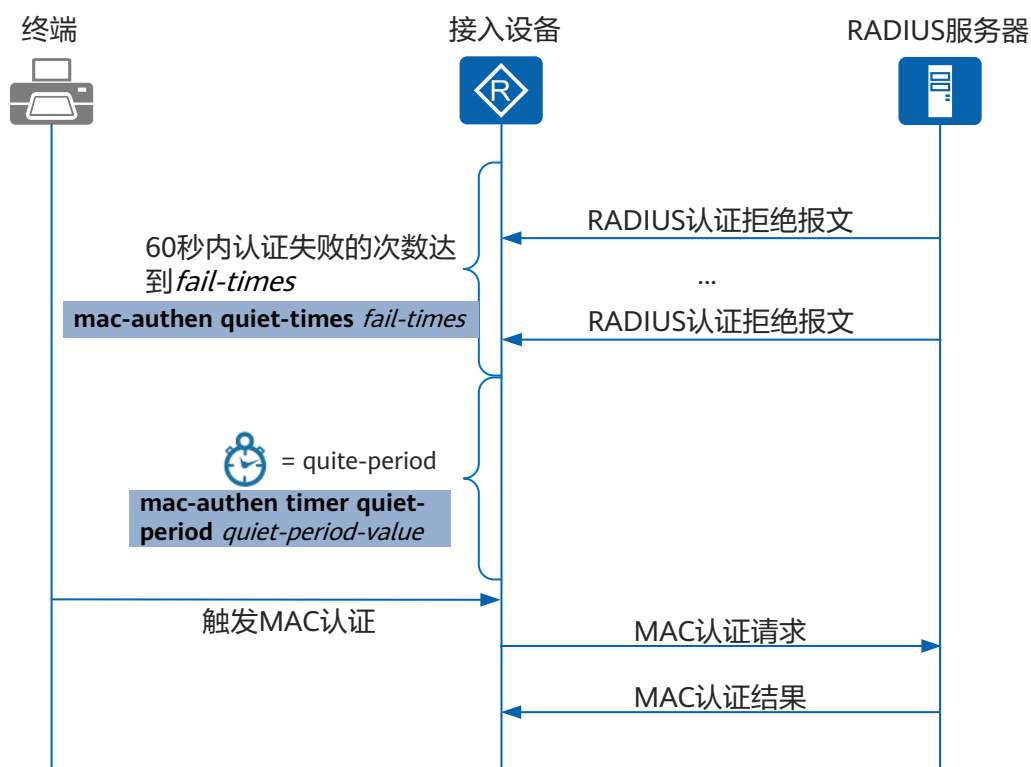
服务器控制用户下线有以下方式：

- RADIUS服务器可通过DM报文（Disconnect Message）强制用户下线。DM（Disconnect Message）是指用户离线报文，即由RADIUS服务器端主动发起的强制用户下线的报文。
- RADIUS服务器通过授权RADIUS标准属性Session-Timeout和Termination-Action。其中，Session-Timeout为用户在线时长定时器，Termination-Action属性值为0表示将用户下线。当用户在线的时长达到定时器指定的数值时，设备会将用户下线。

3.1.3.6 MAC 认证静默定时器

如图3-17所示，在MAC认证过程中，若用户在短时间内频繁认证失败，一方面会占用过多的系统资源，另一方面存在攻击者通过多次尝试输入用户名和密码的方式暴力破解用户名和密码的风险。使能静默功能后，若某一用户在60秒内认证失败的次数达到指定值，则设备会将该用户静默一段时间，静默期间，设备会丢弃该用户的MAC认证请求。

图 3-17 MAC 认证静默流程



3.1.4 Portal 认证原理描述

3.1.4.1 Portal 认证简介

定义

Portal认证通常也称为Web认证，一般将Portal认证网站称为门户网站。用户上网时，必须在门户网站进行认证，如果未认证成功，仅可以访问特定的网络资源，认证成功后，才可以访问其他网络资源。

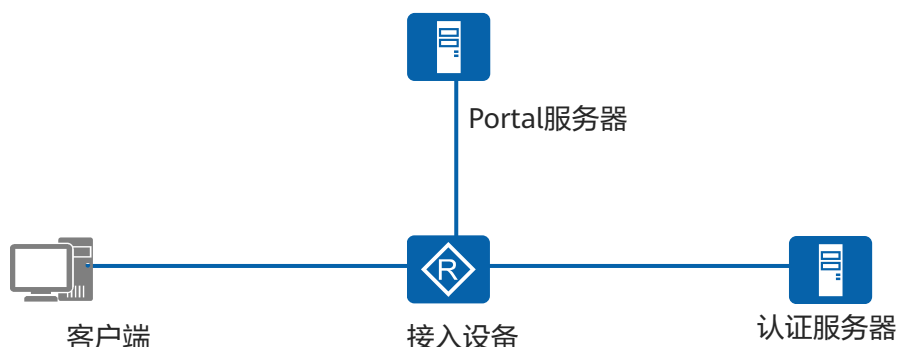
优点

- 一般情况下，客户端不需要安装额外的软件，直接在Web页面上认证，简单方便。
- 便于运营，可以在Portal页面上进行业务拓展，如广告推送、企业宣传等。
- 技术成熟，被广泛应用于运营商、连锁快餐、酒店、学校等网络。
- 部署位置灵活，可以在接入层或关键数据的入口作访问控制。
- 用户管理灵活，可基于用户名与VLAN/IP地址/MAC地址的组合对用户进行认证。

认证系统

Portal认证系统如图3-18所示，其主要包括四个基本要素：客户端、接入设备、Portal服务器与认证服务器。

图 3-18 Portal 认证系统组网图



- 接入设备：交换机、路由器等接入设备的统称，主要有三方面的作用。
 - 在认证之前，将认证网段内用户的所有HTTP/HTTPS请求都重定向到Portal服务器。
 - 在认证过程中，与Portal服务器、认证服务器交互，完成对用户身份认证、授权与计费的功能。
 - 在认证通过后，允许用户访问被管理员授权的网络资源。
- Portal服务器：接收客户端认证请求的服务器系统，提供免费门户服务和认证界面，与接入设备交互客户端的认证信息。
- 认证服务器：与接入设备进行交互，完成对用户的认证、授权与计费。

说明

Portal服务器可以是接入设备之外的独立实体（外置Portal服务器），也可以是存在于接入设备之内的内嵌实体（内置Portal服务器）。内置Portal服务器的接入设备实现了简单的Portal服务器功能，仅能给用户通过Web方式上线、下线的基本功能，并不能完全替代独立的Portal服务器，也不支持外置独立服务器的任何扩展功能，例如不支持MAC优先的Portal认证。

通过内置Portal服务器进行Portal认证，由于不需要部署额外的Portal服务器，故增强了Portal认证的通用性。但是，受限于接入设备存储空间、功能和性能，内置Portal服务器适用于功能简单、接入人数少的场景，例如小型餐馆提供的连接Internet服务。

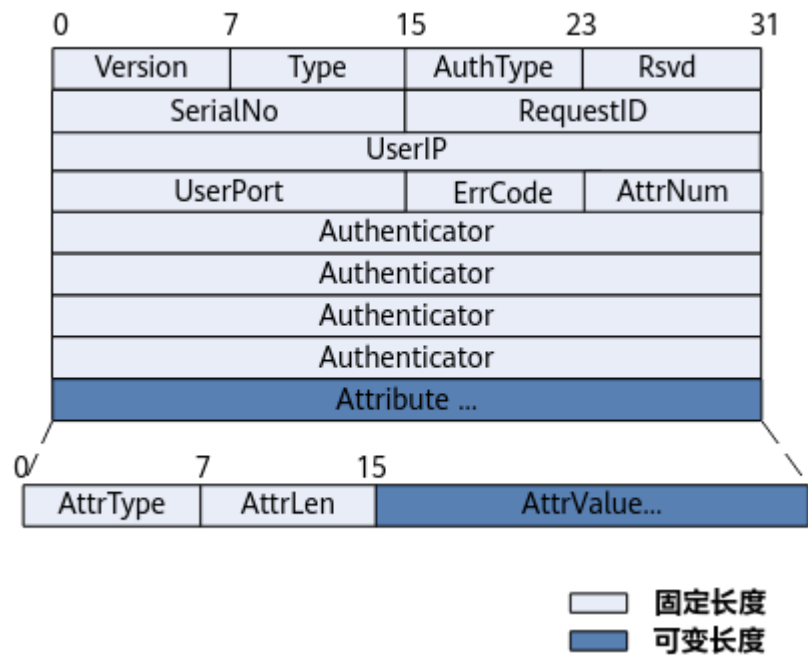
3.1.4.2 Portal 认证协议

3.1.4.2.1 Portal 协议

报文格式

Portal协议报文由固定长度头和可变长度的属性字段组成，属性字段采用TLV（Type-Length-Value）格式。其报文格式如图3-19所示。

图 3-19 报文格式



报文字段

Version

Portal协议的版本号，长度为1字节，默认取值为0x02。

Type

Portal协议的报文类型，长度为1字节。

报文类型	取值	含义
REQ_CHALLENGE	0x01	Portal服务器向接入设备发送的Challenge请求报文
ACK_CHALLENGE	0x02	接入设备对Portal服务器Challenge请求的响应报文
REQ_AUTH	0x03	Portal服务器向接入设备发送的认证请求报文
ACK_AUTH	0x04	接入设备对Portal服务器认证请求的响应报文
REQ_LOGOUT	0x05	Portal服务器向接入设备发送的下线请求报文
ACK_LOGOUT	0x06	接入设备对Portal服务器下线请求的响应报文
AFF_ACK_AUTH	0x07	Portal服务器向接入设备发送的认证成功响应报文

报文类型	取值	含义
NTF_LOGOUT	0x08	接入设备向Portal服务器发送的用户被强制下线通知报文
REQ_INFO	0x09	Portal服务器向接入设备发送的信息询问报文
ACK_INFO	0x0a	接入设备对Portal服务器信息询问的应答报文
ACK_NTF_LOGOUT	0x0e	Portal服务器通知接入设备用户强制下线成功
USER_SYN	0x10	Portal服务器向接入设备发送的用户信息同步请求报文
ACK_USER_SYN	0x11	接入设备对Portal服务器用户信息同步请求的响应报文
STATUS_NOTIFY	0x81	Portal服务器定时向接入设备发送的状态通知报文
ACK_STATUS_NOTIFY	0x82	接入设备对Portal服务器状态通知报文的响应报文
MAC_QUERY	0x30	接入设备对Portal服务器查询MAC缓存报文
ACK_MAC_QUERY	0x31	Portal服务器给接入设备发送的MAC缓存查询回应报文

AuthType

认证方式，长度为1字节。设备支持两种认证方式：

- CHAP认证：取值为0，是一种三次握手认证，它采用密文方式传输用户名和密码。
- PAP认证：取值为0x01，是一种两次握手认证，它采用明文方式传输用户名和密码。

CHAP认证方式才有REQ_CHALLENGE和ACK_CHALLENGE的交互步骤。CHAP认证保密性较好，更为安全可靠。如果是基于安全性的考虑，建议采用该方式。

Rsvd

目前为保留字段，长度为1字节，在所有报文中取值为0。

SerialNo

报文的序列号，长度为2字节，由Portal服务器随机生成。Portal服务器必须保证在同一个认证流程中所有报文的序列号相同；在不同认证流程中的报文序列号在一定时间内不得重复。

RequestID

报文ID，长度为2字节，由接入设备生成，RequestID不会重复。

UserIP

Portal用户的IP地址，长度为4字节。

UserPort

目前为保留字段，长度为2字节，在所有报文中取值为0。

ErrCode

错误码，长度为1字节。其和Type字段一起表示一定的意义。

- Type值为0x01、0x03、0x07、0x09、0x0e、0x10、0x11、0x30、0x31、0x81、0x82时
ErrCode字段无意义，取值为0。
- Type值为0x02时
 - ErrCode值为0，表示接入设备通知Portal服务器Challenge请求成功。
 - ErrCode值为0x01，表示接入设备通知Portal服务器Challenge请求被拒绝。
 - ErrCode值为0x02，表示接入设备通知Portal服务器此链接已建立。
 - ErrCode值为0x03，表示接入设备通知Portal服务器有一个用户正在认证过程中，请稍后再试。
 - ErrCode值为0x04，表示接入设备通知Portal服务器此用户Challenge请求失败。
 - ErrCode值为0xfd，表示接入设备通知Portal服务器未找到此用户（用户已漫游或下线）。
- Type值为0x04时
 - ErrCode值为0，表示接入设备通知Portal服务器此用户认证成功。
 - ErrCode值为0x01，表示接入设备通知Portal服务器此用户认证请求被拒绝。
 - ErrCode值为0x02，表示接入设备通知Portal服务器此链接已建立。
 - ErrCode值为0x03，表示接入设备通知Portal服务器有一个用户正在认证过程中，请稍后再试。
 - ErrCode值为0x04，表示接入设备通知Portal服务器此用户认证失败（发生错误，例如用户名错误）。
 - ErrCode值为0x05，表示接入设备通知Portal服务器此用户认证失败（Portal在线用户数已达到最大值）。
 - ErrCode值为0x06，表示接入设备通知Portal服务器此用户认证失败（设备正在对该终端进行其他方式的认证）。
 - ErrCode值为0xfd，表示接入设备通知Portal服务器未找到此用户（用户已漫游或下线）。
- Type值为0x05时
 - ErrCode值为0，表示Portal服务器发给接入设备的请求下线报文。
 - ErrCode值为0x01，表示Portal服务器没有收到接入设备对各种请求的响应报文时，定时器超时后Portal服务器发给接入设备的报文。

- Type值为0x06时
 - ErrCode值为0，表示接入设备通知Portal服务器此用户下线成功。
 - ErrCode值为0x01，表示接入设备通知Portal服务器此用户下线被拒绝。
 - ErrCode值为0x02，表示接入设备通知Portal服务器此用户下线失败。
- Type值为0x08时
 - ErrCode值为0x02，表示接入设备通知Portal服务器此用户被强制下线。
- Type值为0x0a时
 - ErrCode值为0，表示接入设备通知Portal服务器此询问消息处理成功。
 - ErrCode值为0x01，表示接入设备通知Portal服务器此询问消息处理失败（不支持该功能）。
 - ErrCode值为0x02，表示接入设备通知Portal服务器此询问消息处理失败（发生错误，例如询问消息格式错误）。

AttrNum

属性字段中属性的个数，长度为1字节，属性字段中最多有255个属性。

Authenticator

验证字，长度为16字节。其是通过MD5算法对各字段计算后得出的数据。

Attribute

一个可变长字段，由多个属性组合而成，每个属性的格式为TLV格式。

- AttrType：属性类型，长度为1字节。
- AttrLen：属性字段的长度，长度为1字节，其值是AttrType、AttrLen、AttrValue三个字段的长度之和。
- AttrValue：具体的属性值，如下表所示。例如用户名、密码等，长度有些可变，有些固定，但最长不能超过253字节。

Attribute	AttrType	AttrValue长度	说明	使用该属性的消息类型
UserName	0x01	1 ~ 253	用户名，具体格式为：“用户名”+“@”+“域名”，例如test@huawei.com	REQ_AUTH
Password	0x02	1 ~ 128	用户提交的密码	REQ_AUTH
Challenge	0x03	16	CHAP方式加密的认证字	ACK_CHALLENGE
ChapPassword	0x04	16	经过CHAP方式加密后的密码	REQ_AUTH

Attribute	AttrType	AttrValue长度	说明	使用该属性的消息类型
TextInfo	0x05	2 ~ 253	用于将RADIUS等第三方鉴权设备的提示信息透传到Portal服务器。该属性所携带的内容为字符串，但是不包括字符串结束符'\0'。该属性在同一个报文中允许出现多个，建议只携带1个该属性。	ACK_AUTH、REQ_AUTH (仅Portal 1.0版本)
Port	0x08	1 ~ 51	端口号，其格式为： - 类型+长度（在REQ_INFO报文） - 类型+长度+内容（在ACK_INFO报文）	REQ_INFO、ACK_INFO
Bas_IP	0x0a	4	用户漫游后的AC IP地址	ACK_AUTH、ACK_CHALLENGE
User_Mac	0x0b	6	用户的MAC地址	ACK_AUTH、ACK_LOGOUT、NTF_LOGOUT、ACK_CHALLENGE、ACK_INFO、REQ_CHALLENGE、REQ_AUTH、REQ_LOGOUT
User_Private_IP	0x0d	4 ~ 252	用户的IPv4地址	USER_SYN、ACK_USER_SYN
WebAuthenInfo	0x40	1 ~ 247	用于将用户在Web页面上的输入传递给RADIUS服务器，可携带多个	REQ_AUTH
User_IPV6	0xf1	16	用户的IPv6地址	REQ_CHALLENGE、ACK_CHALLENGE、REQ_AUTH、ACK_AUTH、REQ_LOGOUT、ACK_LOGOUT、AFF_ACK_AUTH、NTF_LOGOUT、REQ_INFO、ACK_INFO

3.1.4.3 Portal 认证方式

按照网络中实施Portal认证的网络层次来分，Portal认证方式分为两种：二层认证方式和三层认证方式。

- 当客户端与接入设备之间为二层网络时，即客户端与接入设备直连（或之间只有二层设备存在），接入设备可以学习到客户端的MAC地址，则接入设备可以利用IP地址和MAC地址来识别用户，此时可配置Portal认证为二层认证方式。
二层认证流程简单，安全性高，但由于限制了用户只能与接入设备处于同一网段，所以组网灵活性不高。
- 当客户端与接入设备之间包含三层网络时，即客户端与接入设备之间存在三层转发设备，接入设备不能获取到认证客户端的MAC地址，只能以IP地址作为用户的唯一标识，此时需要将Portal认证配置为三层认证方式。
三层认证组网灵活，容易实现远程控制，但由于只能以IP地址作为用户的唯一标识，所以安全性不高。

3.1.4.4 Portal 认证流程

认证的第一件事情就是发起认证，有两种认证触发方式：

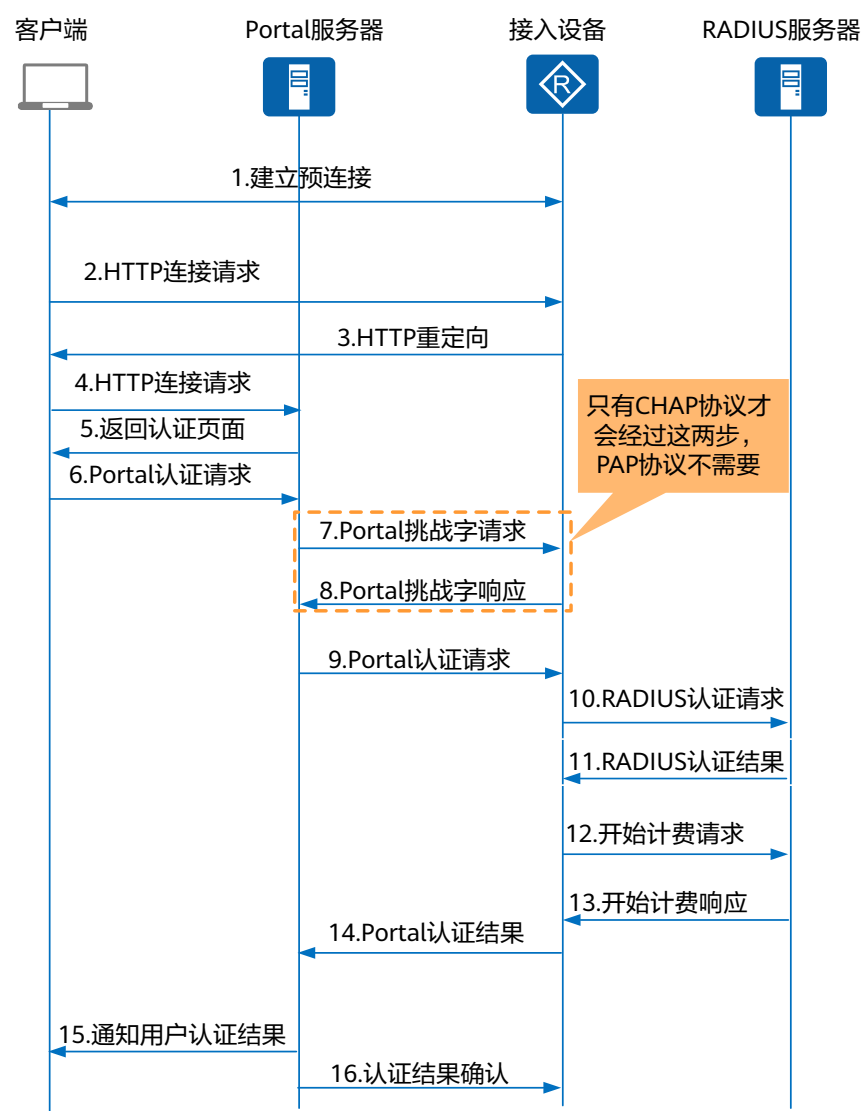
- 主动认证
用户通过浏览器主动访问Portal认证网站时，即在浏览器中直接输入Portal服务器的网络地址，然后在显示的网页中输入用户名和密码进行认证，这种开始Portal认证过程的方式即为主动认证，即由用户自己主动访问Portal服务器发起的身份认证。
- 重定向认证
用户输入的访问地址不是Portal认证网站地址时，将被强制访问Portal认证网站（通常称为重定向），从而开始Portal认证过程，这种方式称作重定向认证。

3.1.4.4.1 基于 Portal 协议的 Portal 认证流程

这里主要介绍外置Portal服务器的二层认证流程。对于内置Portal服务器的认证流程，与外置Portal服务器的认证流程类似，这里不再赘述。

在二层认证方式下，用户上线时的报文交互流程如[图3-20](#)所示。对于三层认证方式，客户端与接入设备之间没有建立预连接过程，其余报文处理流程跟二层认证完全一致。

图 3-20 基于 Portal 协议的 Portal 认证流程图



- 1. 在认证之前客户端与接入设备之间建立起预连接，即客户端用户在认证成功之前在接入设备上已建立用户在线表项，并且只有部分网络访问权限。
- 2. 客户端发起HTTP连接请求。
- 3. 接入设备收到HTTP连接请求报文时，如果是访问Portal服务器或免认证网络资源的HTTP报文，则接入设备允许其通过；如果是访问其它地址的HTTP报文，则接入设备将其URL地址重定向到Portal认证页面。
- 4. 客户端根据获得的URL地址向Portal服务器发起HTTP连接请求。
- 5. Portal服务器向客户端返回Portal认证页面。
- 6. 用户在Portal认证页面输入用户名和密码后，客户端向Portal服务器发起Portal认证请求。
- 7. （可选）Portal服务器收到Portal认证请求后，如果Portal服务器与接入设备之间采用CHAP认证，则Portal服务器向接入设备发起Portal挑战字请求报文（REQ_CHALLENGE）；如果Portal服务器与接入设备之间采用PAP认证，则接入设备直接进行第9步。

说明

Portal挑战字请求使用的共享密钥是通过**shared-key**命令配置的，请确保共享密钥配置正确，并且和Portal服务器保持一致。

8. （可选）接入设备向Portal服务器回应Portal挑战字应答报文（ACK_CHALLENGE）。
9. Portal服务器将用户输入的用户名和密码封装在Portal认证请求报文（REQ_AUTH）中，并发送给接入设备。
10. 接入设备根据获取到的用户名和密码，向RADIUS服务器发送RADIUS认证请求（ACCESS-REQUEST）。
11. RADIUS服务器对用户名和密码进行认证。如果认证成功，则RADIUS服务器向接入设备发送认证接受报文（ACCESS-ACCEPT）；如果认证失败，则RADIUS服务器返回认证拒绝报文（ACCESS-REJECT）。
由于RADIUS协议合并了认证和授权的过程，因此认证接受报文中也包含了用户的授权信息。
12. 接入设备根据接收到的认证结果接入/拒绝用户。如果允许用户接入，则接入设备向RADIUS服务器发送计费开始请求报文（ACCOUNTING-REQUEST）。
13. RADIUS服务器返回计费开始响应报文（ACCOUNTING-RESPONSE），并开始计费，将用户加入自身在线用户列表。
14. 接入设备向Portal服务器返回Portal认证结果（ACK_AUTH），并将用户加入自身在线用户列表。
15. Portal服务器向客户端发送认证结果报文，通知客户端认证成功，并将用户加入自身在线用户列表。
16. Portal服务器向接入设备发送认证应答确认（AFF_ACK_AUTH）。

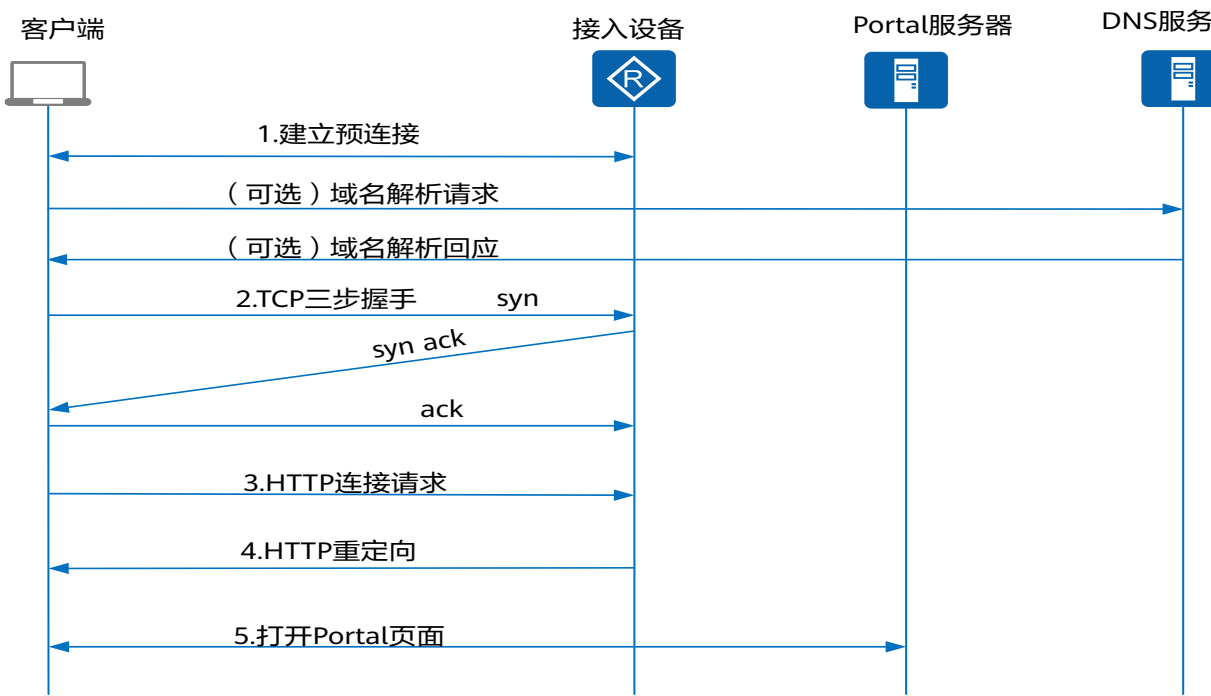
3.1.4.4.2 基于 HTTP/HTTPS 协议的 Portal 重定向流程

基于 HTTP 协议的 Portal 重定向流程

HTTP是一个网络应用层协议，基于请求与响应、无状态、应用层协议，常基于TCP/IP协议传输数据，互联网应用最为广泛的一种网络协议。

HTTP的交互过程较为简单，TCP三步握手成功之后，即开始HTTP访问过程，如图3-21所示。

图 3-21 HTTP 建链过程



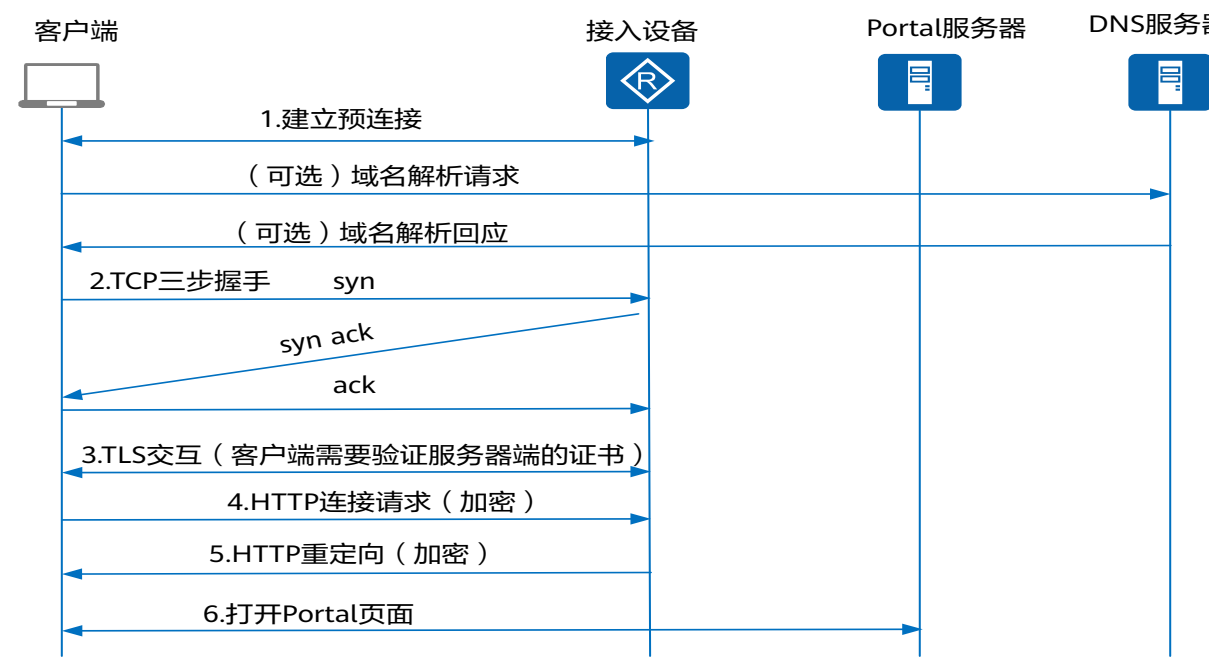
说明

- 当客户端访问的原始URL是域名时，需要DNS服务器解析域名，设备上free-rule需要放行DNS服务器的IP。当客户端访问的原始URL是IP时，则不需要该步骤。
- 客户端刚建立预链接时，通过HTTP探测自己客户端厂家的域名是否可达，此时触发HTTP重定向，自动弹出Portal页面。

基于 HTTPS 协议的 Portal 重定向流程

HTTPS的重定向过程比HTTP重定向多了TLS(Transport Layer Security，传输层安全)建链过程，在TLS协商过程中客户端需要验证服务器端的证书，而服务器端的证书是需要到合法的证书颁发机构购买并与网站（域名）绑定，以防止其他网站或者中间的拦截者进行网站仿冒，保证是与合法的服务器通信，协商成功后，后续的HTTP报文均在加密的SSL通道中传输，保证传输信息的保密性。

图 3-22 HTTPS 建链过程



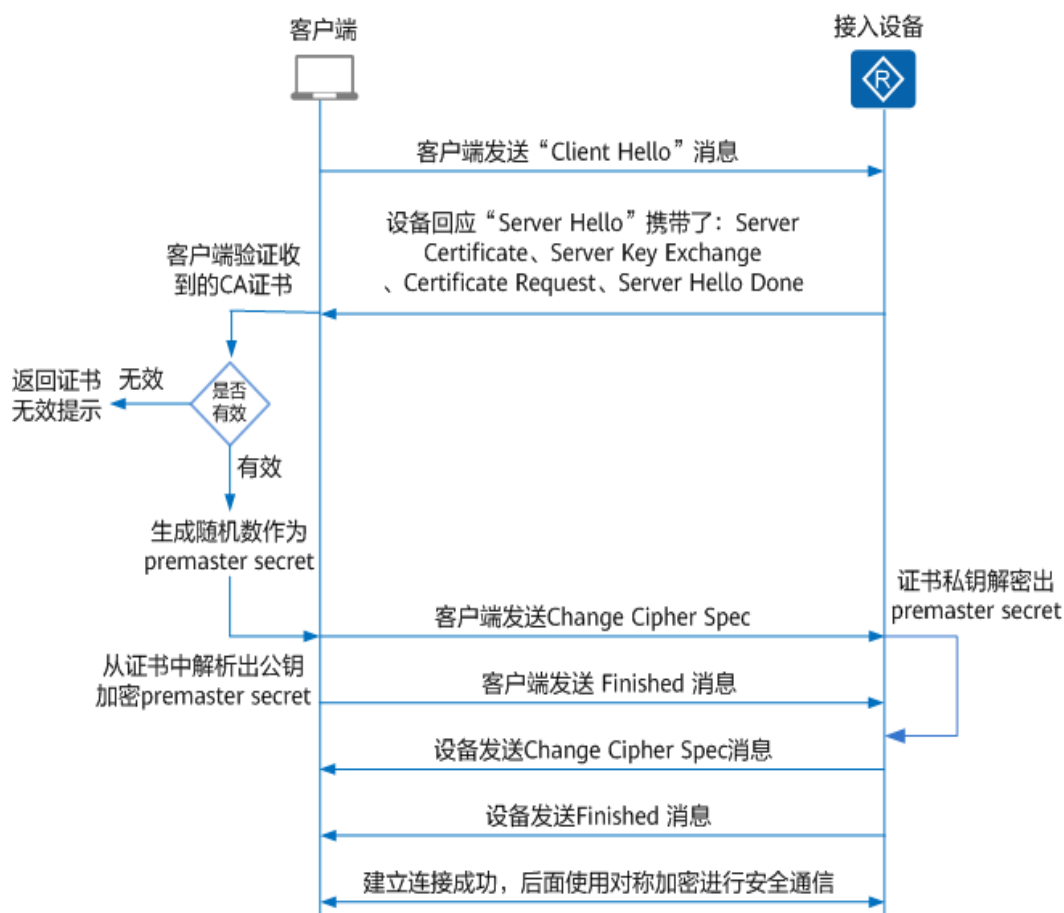
说明

- 当客户端访问的原始URL是域名时，需要DNS服务器解析域名，设备上free-rule需要放行DNS服务器的IP。当客户端访问的原始URL是IP时，则不需要该步骤。
- 客户端刚建立预链接时，访问HTTPS门户网站例如谷歌百度等，此时触发HTTPS重定向。

其中，TLS交互如图3-23所示，包含如下步骤：

1. 交换加密参数；
2. 验证服务端证书；
3. 交换数据密钥。

图 3-23 TLS 交互过程



说明

客户端收到设备返回的证书后，浏览器会弹出“您的连接不是私密连接”的告警，此时需要客户点击浏览器上“高级-继续前往”访问Portal服务器。弹出该告警的原因是接入设备拦截客户端的原始HTTPS请求后仿冒HTTPS网站回应，在回应报文中使用设备证书，该证书不是权威机构颁发，不在客户端信任证书范围内。受客户端信任的证书由权威机构颁发并且需要包含HTTPS网站的URL，设备无法预知客户端访问的原始页面URL，设备证书也就无法包含HTTPS网站的URL，因此该告警无法避免。

3.1.4.5 Portal 认证授权

认证用于确认尝试接入网络的用户身份是否合法，而授权则用于指定身份合法的用户所能拥有的网络访问权限，即用户能够访问哪些资源。授权最基础也是最常用的参数是ACL和UCL组，此处以RADIUS授权进行说明，其他授权方式的授权方法以及更多可授权的参数请参见[AAA授权方案](#)。

free-rule

用户认证成功之前，为满足用户基本的网络访问需求，需要用户认证成功前就能获取部分网络访问权限。可在free-rule模板中配置free-rule规则，满足用户的认证成功前的网络访问需求。

3.1.4.6 Portal 认证用户下线

- 当用户已下线，而接入设备、RADIUS服务器和Portal服务器未感知到该用户已下线时，会产生以下问题：
- RADIUS服务器仍会对该用户进行计费，造成误计费。
 - 存在非法用户仿冒合法用户IP地址和MAC地址接入网络的风险。
 - 已下线用户数量过多的情况下，还会占用设备用户规格，可能会导致其他用户无法接入网络。

因此，接入设备要能够及时感知到用户已下线，删除该用户表项，并通知RADIUS服务器停止对该用户进行计费。

用户下线分为客户端主动下线、接入设备控制用户下线、认证服务器强制用户下线和Portal服务器强制用户下线。

客户端主动下线

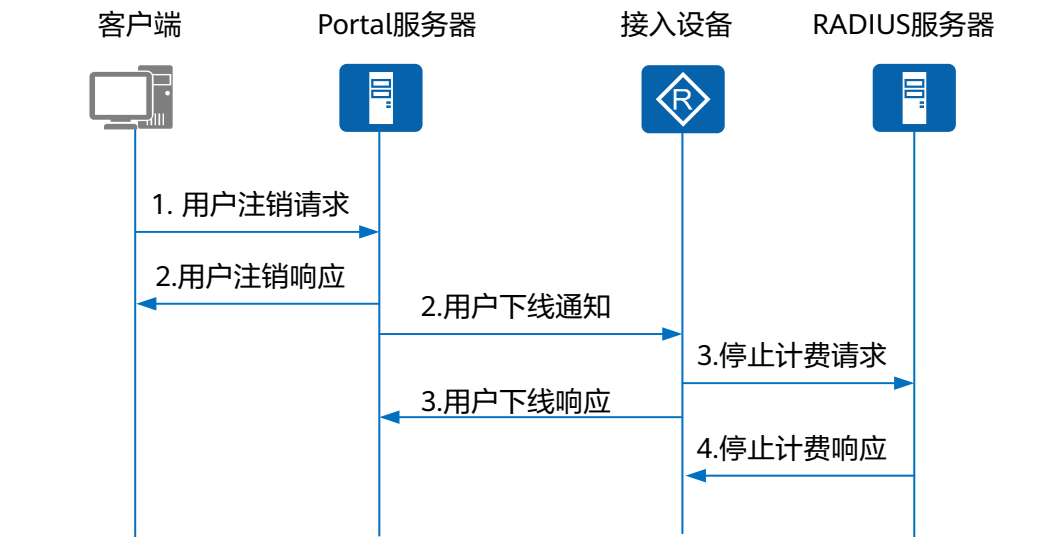
由用户发起的主动下线，例如用户点击注销按钮，客户端向Portal服务器发送用户注销请求。

对于Portal协议，Portal服务器收到用户的下线请求后，会通知客户端下线成功，而不需要等待接入设备对下线的确认。

Portal协议

具体下线流程如图3-24所示。

图 3-24 客户端主动下线流程图



1. 客户端向Portal服务器发送用户注销请求。
2. Portal服务器向客户端发送用户注销响应，并向接入设备发送用户下线通知报文（REQ_LOGOUT）。
3. 接入设备向RADIUS服务器发送停止计费请求报文（ACCOUNTING-REQUEST），并将用户下线。同时，接入设备向Portal服务器发送用户下线响应报文（ACK_LOGOUT）。

Portal服务器收到用户下线响应后，将用户下线。

4. RADIUS服务器返回停止计费响应报文（ACCOUNTING-RESPONSE），并将用户下线。

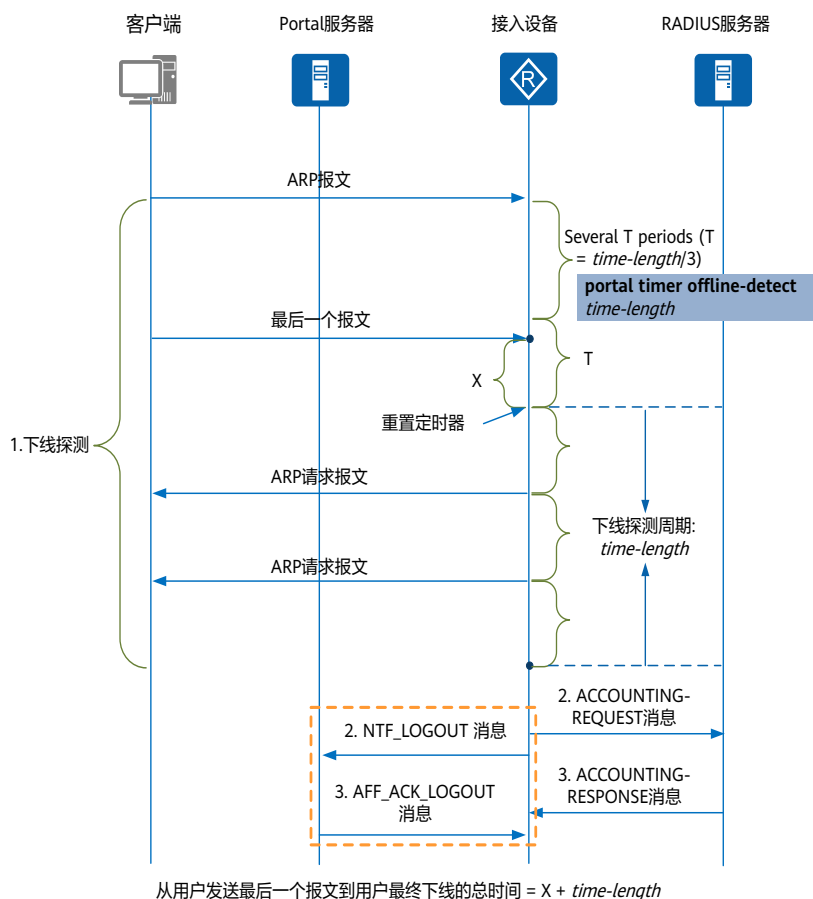
接入设备控制用户下线

接入设备控制用户下线有两种方式：

- 在接入设备上执行命令**cut access-user**强制指定用户下线。
- 在接入设备上配置用户探测功能，用于探测用户是否在线。当用户在指定的时间内无响应，则认为用户下线，删除用户表项。

具体下线流程如图3-25所示。这里以Portal协议为例介绍下线探测的下线流程。

图 3-25 用户下线探测流程图



- ### 1. 下线探测过程。

接入设备获取到客户端IP地址，启动下线探测定时器，周期为 $time-length$ （三层Portal认证的握手周期通过命令**authentication timer handshake-period $time-length$** 进行配置，探测方式为ICMP报文探测；二层Portal认证用户的握手周期通过命令**portal timer offline-detect $time-length$** ，探测方式为ARP报文探测）。假如握手周期为 $3T$ ，则设备会在 T 、 $2T$ 时刻进行用户探测。以 $0 \sim T$ 时间段为例， $T \sim 2T$ 与之类似，不再赘述。

- 如果在0~T时间段内，有用户流量经过设备，则在T时刻，设备认为用户在线，该时刻设备不会再发送探测报文，并重置探测定时器（即3T）周期。
- 如果在0~T时间段内，没有用户流量经过设备，则在T时刻，设备无法感知到用户是否在线，该时刻设备会发送探测报文（对于三层Portal认证，此时刻设备不发探测报文，再等到3T时间后还是没有用户流量经过设备，则直接认为用户已下线）。如果设备收到用户的回应报文，则认为用户在线，并重置探测定时器；如果未收到，则认为用户已下线。
- 如果在2T~3T时间段内，有用户流量经过设备，则在3T时刻，设备认为用户在线，该时刻设备重置探测定时器。
- 如果在2T~3T时间段内，没有用户流量经过设备，则在3T时刻，设备无法感知到用户是否在线，认为用户已下线。

如果在T、2T、3T时刻，设备均认为用户已下线，则设备会删除该用户的所有相关表项。为防止用户PC闲置时被异常下线，请不要将握手周期设置的过小，推荐使用默认值。

2. 接入设备向Portal服务器发送用户下线通知（NTF_LOGOUT），并将用户下线。同时，接入设备向RADIUS服务器发送停止计费请求报文（ACCOUNTING-REQUEST）。
3. Portal服务器向接入设备发送用户下线响应报文（AFF_ACK_LOGOUT），并将用户下线。RADIUS服务器向接入设备发送停止计费响应报文（ACCOUNTING-RESPONSE），并将用户下线。

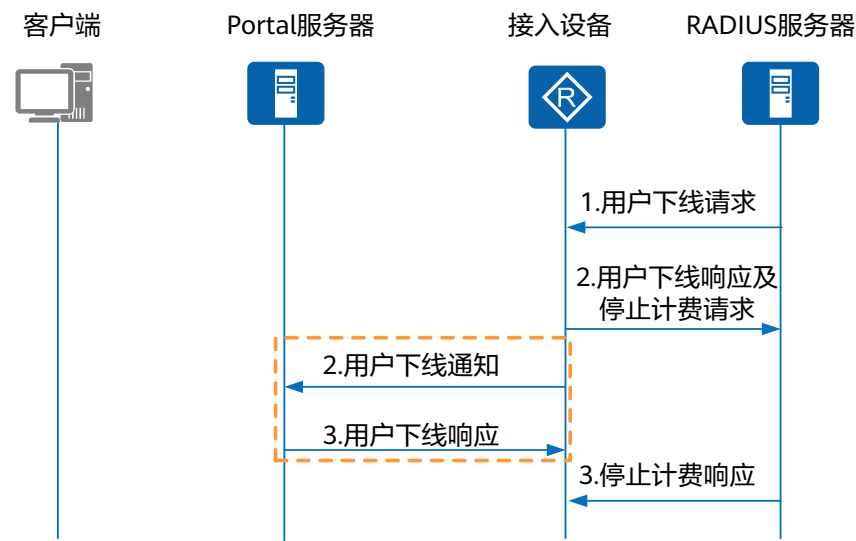
认证服务器强制用户下线

服务器强制用户下线有以下方式：

- RADIUS服务器可通过DM报文（Disconnect Message）强制用户下线。DM是指用户离线报文，即由RADIUS服务器端主动发起的强制用户下线的报文。
- RADIUS服务器通过授权RADIUS标准属性Session-Timeout和Termination-Action。其中，Session-Timeout为用户在线时长定时器，Termination-Action属性值为0表示将用户下线。当用户在线的时长达到定时器指定的数值时，设备会将用户下线。

具体下线流程如[图3-26](#)所示，以RADIUS服务器通过DM报文强制用户下线为例。

图 3-26 认证服务器强制用户下线流程图



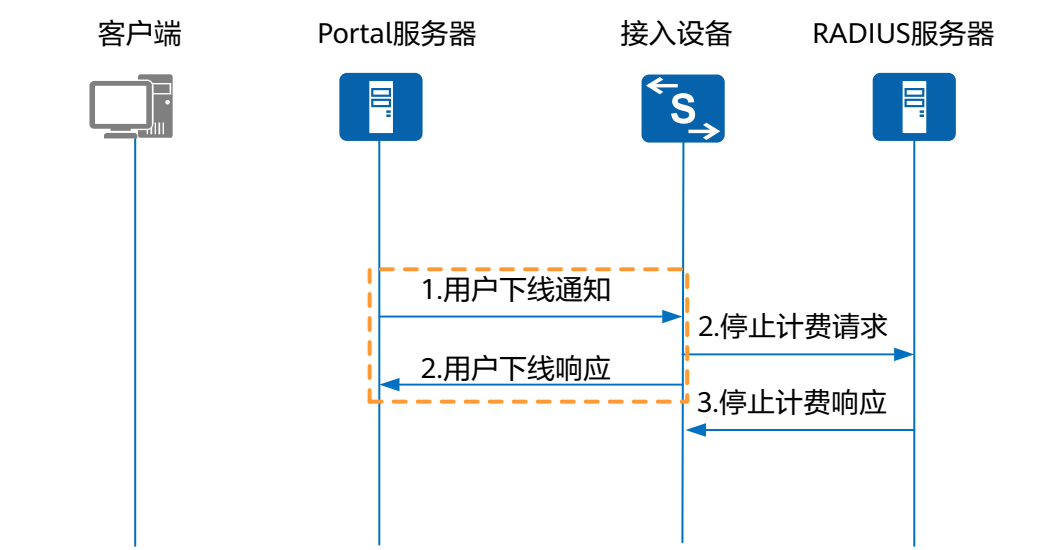
1. RADIUS服务器向接入设备发送用户下线请求（DM Request）。
2. 接入设备向Portal服务器发送下线通知（NTF_LOGOUT），并将用户下线。同时，接入设备向RADIUS服务器发送下线响应（DM ACK）及停止计费请求报文（ACCOUNTING-REQUEST）。
3. Portal服务器向接入设备发送用户下线响应报文（AFF_ACK_LOGOUT），并将用户下线。RADIUS服务器向接入设备发送停止计费响应报文（ACCOUNTING-RESPONSE），并将用户下线。

Portal 服务器强制用户下线

当管理员注销用户或Portal服务器主动探测发现用户已经离线等事件发生时，Portal服务器将用户下线，并向接入设备发送下线通知。

具体下线流程如图3-27所示。这里以使用Portal协议的Portal服务器为例介绍下线流程。

图 3-27 Portal 服务器强制用户下线流程图



1. Portal服务器向接入设备发送用户下线通知报文（REQ_LOGOUT）。
2. 接入设备向RADIUS服务器发送停止计费请求报文（ACCOUNTING-REQUEST），并将用户下线。同时，接入设备向Portal服务器发送用户下线响应报文（ACK_LOGOUT）。
- Portal服务器收到用户下线响应后，将用户下线。
3. RADIUS服务器返回停止计费响应报文（ACCOUNTING-RESPONSE），并将用户下线。

3.1.4.7 Portal 定时器

如表3-10所示，接入设备支持以下Portal定时器。

表 3-10 Portal 定时器

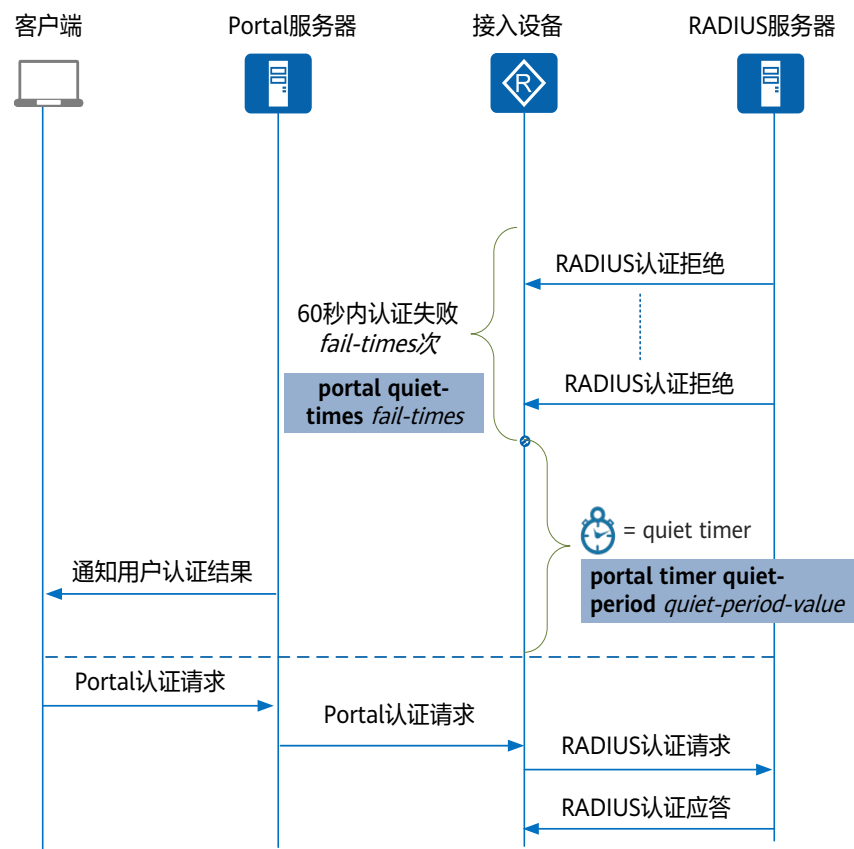
Portal定时器	功能	适用场景
用户静默定时器	用来防止用户认证失败时频繁认证，形成了一种DoS攻击，浪费系统资源。	适用于使用Portal协议的外置Portal服务器，或者使用Portal协议的内置Portal服务器场景。
Portal服务器探测定时器	用来防止接入设备与Portal服务器之间出现网络故障导致通信中断或Portal服务器本身出现故障时，已经在线的Portal用户无法正常下线或新的Portal认证用户无法上线。	适用于使用Portal协议的外置Portal服务器场景。

Portal定时器	功能	适用场景
用户信息同步定时器	用来防止接入设备与Portal服务器之间出现网络故障导致通信中断或Portal服务器本身出现故障时，已经在线的Portal用户无法正常下线，造成接入设备与Portal服务器用户信息不一致以及计费不准确问题。	适用于使用Portal协议的外置Portal服务器场景。
用户下线重传定时器	用来防止接入设备与Portal服务器之间的网络不稳定、存在丢包等现象时，Portal服务器接收不到接入设备发送的用户下线报文，出现用户在接入设备上显示已经下线，在Portal服务器上显示仍然在线的情况。	适用于使用Portal协议的外置Portal服务器场景。
内置Portal服务器心跳探测定时器	用来防止用户关闭浏览器、网络异常断开等缘故造成用户下线时，接入设备上仍保留该用户信息，造成计费不准确或其他用户无法上线等问题。	适用于使用Portal协议的内置Portal服务器场景。

用户静默定时器

用户在60秒内认证失败的次数超过指定的次数（通过命令`portal quiet-times fail-times`）时，接入设备会将该用户静默一段时间（通过命令`portal timer quiet-period quiet-period-value`配置），在静默期间，接入设备会丢弃该用户的Portal认证请求。具体静默流程如[图3-28](#)所示，以使用Portal协议认证为例。

图 3-28 用户被静默流程图



Portal 服务器探测定时器

设备对Portal服务器的探测方式有Portal方式和HTTP方式两种。对于采用Portal协议的Portal认证，设备两种探测方式都支持，对于HTTP/HTTPS方式的Portal认证，仅支持HTTP方式的探测。

Portal方式的Portal服务器探测：Portal服务器定期发送心跳报文给接入设备，接入设备通过检测此报文来判断服务器的可达状态，如果接入设备在指定的探测周期内（通过命令**server-detect interval interval-period**）收到Portal心跳报文或者其它认证报文，则认为此次探测成功且服务器可达（状态为Up），否则认为此次探测失败。当对某一Portal服务器连续探测失败次数超过最大次数（通过命令**server-detect max-times times**）时，接入设备会将该Portal服务器的状态由Up改变为Down。

HTTP方式的Portal服务器探测：设备按照探测周期发送HTTP报文给Portal服务器，Portal服务器进行回应，如果接入设备在指定的探测周期内（通过命令**server-detect interval interval-period**配置）收到回应报文，则认为探测成功。否则认为此次探测失败。连续探测失败次数超过最大次数（通过命令**server-detect max-times times**配置）时，接入设备会将该Portal服务器的状态由Up改变为Down。

具体探测流程如图3-29和图3-30所示。

说明

建议在接入设备上配置的Portal服务器探测周期**interval-period**大于在Portal服务器上配置的心跳报文周期T。

图 3-29 Portal 方式的 Portal 服务器探测

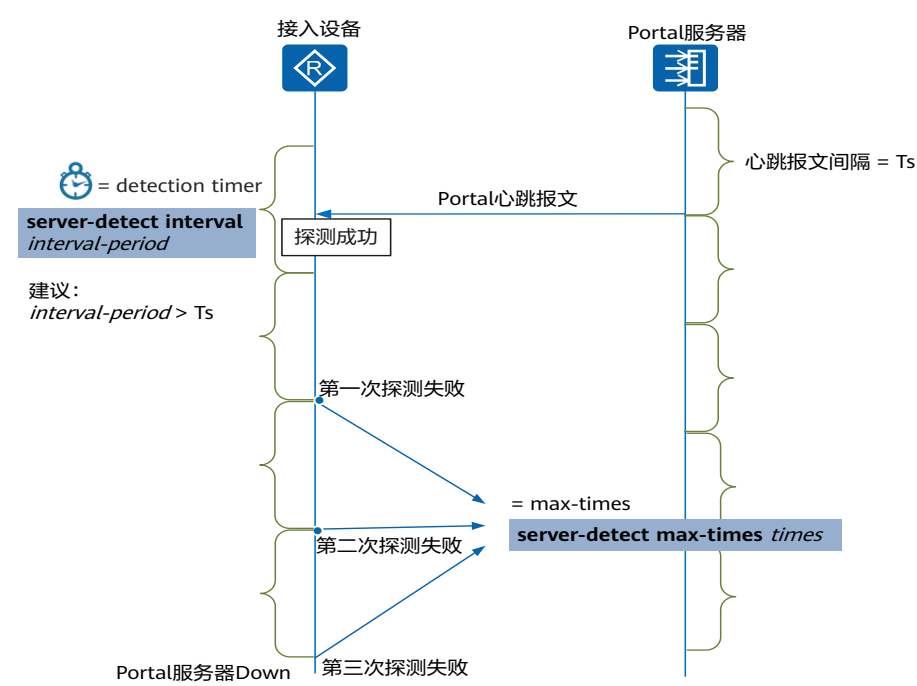
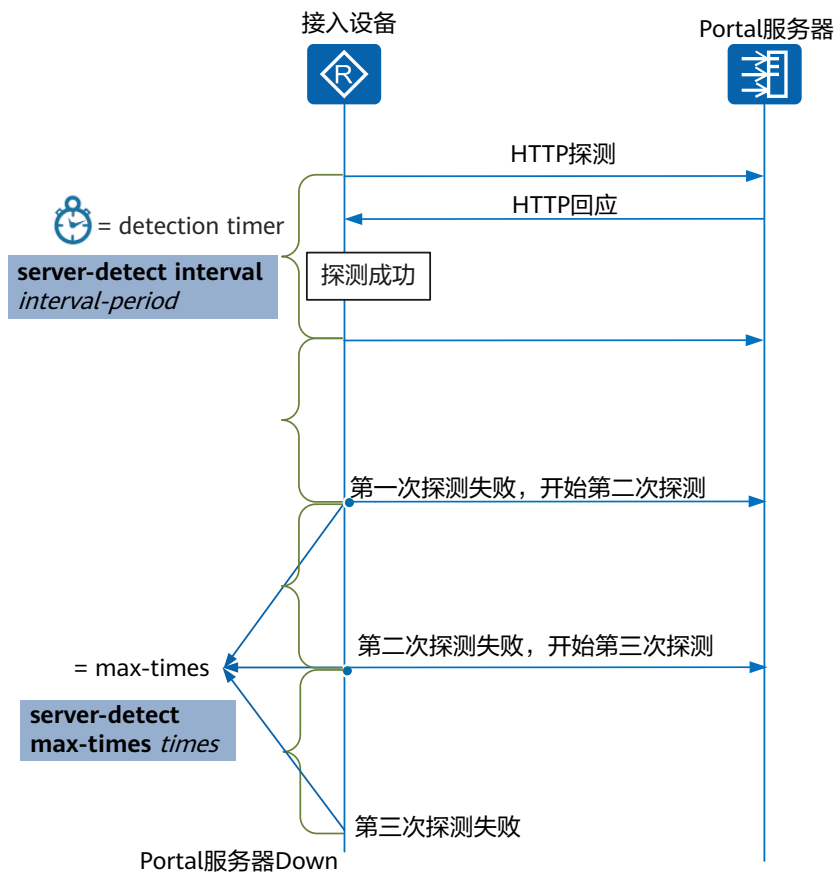


图 3-30 HTTP 方式的 Portal 服务器探测



同时，接入设备将会做出以下动作，使管理员能够实时掌握网络中Portal服务器的状态或保证用户一定的网络访问权限。

- 发送告警：Portal服务器可达或者不可达的状态改变时，发送告警信息给网管，其中记录了Portal服务器IP地址以及该服务器的当前状态。
- 发送日志：Portal服务器可达或者不可达的状态改变时，发送日志信息给网管，其中记录了Portal服务器IP地址以及该服务器的当前状态。
- 启用Portal逃生机制：状态为Up的Portal服务器数目小于或等于设置的最小值（通过命令**server-detect critical-num critical-num**）时，暂时取消接口的Portal认证，允许所有Portal用户访问指定的网络资源，请参见[NAC逃生机制](#)中的“Portal服务器Down”授权。之后，当接入设备收到某Portal服务器的心跳报文，或者收到其它认证报文（例如用户下线报文），或者HTTP探测成功时，接入设备会将该Portal服务器的状态由Down改变为Up，如果状态为Up的Portal服务器数目大于设置的最小值，则恢复该接口的Portal认证功能。

用户信息同步定时器

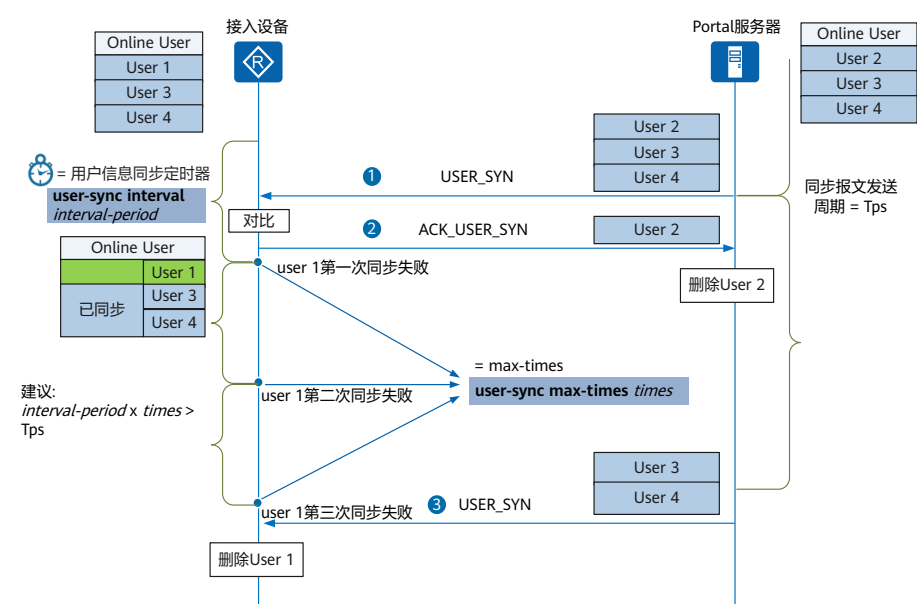
Portal服务器周期性地（周期为Tps）将在线用户信息通过用户信息同步请求报文（USER_SYN）发送给接入设备。接入设备在开启Portal用户信息同步功能之后，即启

动用户信息同步定时器，在用户信息同步周期内（通过命令`user-sync interval interval-period`配置），收到用户同步请求报文后，将其中携带的在线用户信息与自己在线用户信息进行对比。

- 同步请求报文中的用户信息与设备上实际用户信息相同时，则设备不对该同步请求报文进行响应，只是将这些用户标记为已同步。
- 设备上存在未同步用户时，回应同步请求报文。如果在达到同步最大次数（通过命令`user-sync max-times times`配置）仍未同步成功，设备会将该用户强制下线。
- 仅在Portal服务器上存在接入设备上不存在的用户，设备回应同步请求报文，Portal服务器将其删除。

具体同步流程如图3-31所示。

图 3-31 用户信息同步流程图



说明

目前接入设备仅支持和华赛TSM Portal服务器同步用户信息。

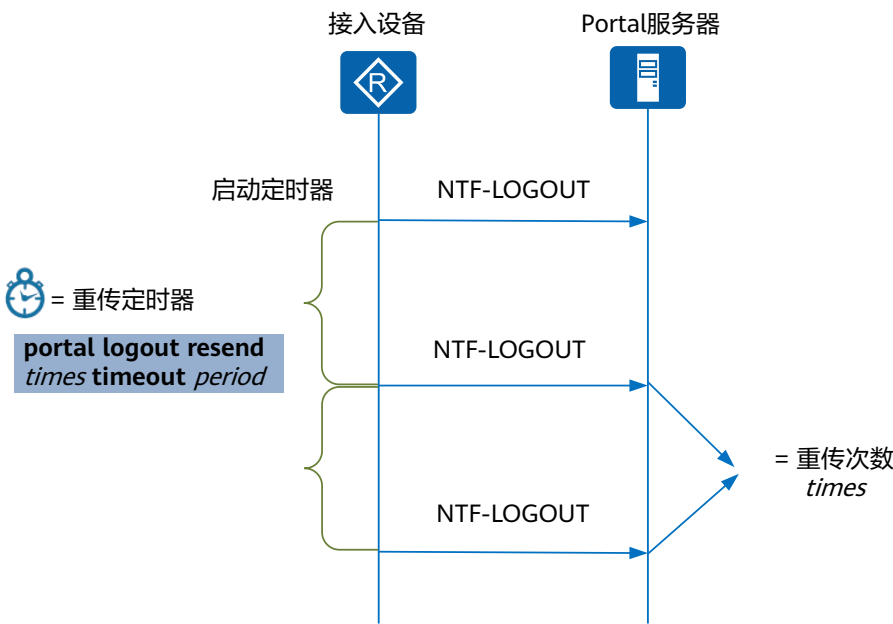
建议接入设备配置的 $interval-period \times times$ 的值应该大于Portal服务器发送同步请求报文的时间间隔，否则设备可能会在达到最大失败次数后，由于收不到Portal服务器的同步请求报文，将用户强制下线。

用户下线重传定时器

为使Portal服务器能够接收到用户下线报文，保证Portal服务器上的用户在线信息正确，接入设备提供用户下线报文重传功能，在用户下线重传周期 $period$ 内，接入设备没有收到Portal服务器的用户下线应答报文，会重传用户下线报文，最多重传 $times$ 次（通过命令`portal logout resend times timeout period`配置）。

具体下线流程如图3-32所示。

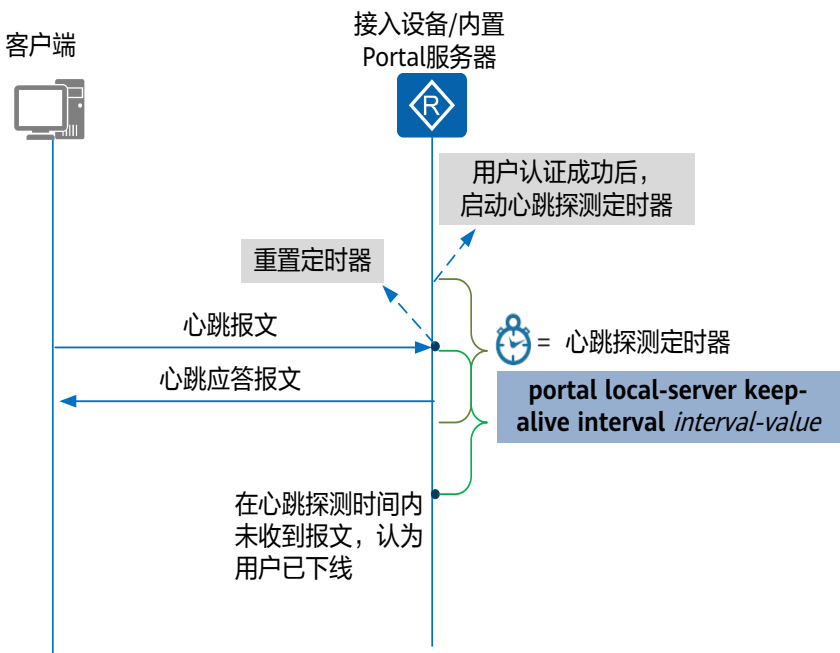
图 3-32 用户下线流程图



内置 Portal 服务器心跳探测定时器

用户认证通过后，推送给用户一个连接保持页面，表示该用户处于认证状态。这个连接保持页面中嵌入心跳程序，定期向接入设备发送心跳报文表示该用户在线。如果在指定的心跳探测时间内（通过命令portal local-server keep-alive interval interval-value配置）接入设备没有收到用户发送的心跳报文或认证报文，则可以认为该用户异常离线，并指定该用户下线。具体心跳探测流程如图3-33所示。

图 3-33 内置 Portal 服务器心跳探测流程图



内置Portal服务器的心跳探测模式分为强制探测模式和自动探测模式。

- 强制探测模式：对于所有用户，如果在指定的时间内接入设备没有收到过用户的心跳报文，则指定用户下线。
- 自动探测模式：设备会检测用户客户端网页浏览器是否支持心跳程序，如果支持，则采用强制探测模式对该用户进行探测；如果不支持，则不对该用户进行探测。建议采用该模式，避免浏览器不支持心跳程序导致用户下线。

说明

目前Windows7系统下浏览器IE8、Firefox3.5.2、Chrome28.0.1500.72、Opera12.00支持心跳程序。

使用Java1.7及以上版本的浏览器不支持心跳程序。

3.1.5 混合认证

3.1.5.1 MAC 旁路认证

简介

MAC旁路认证是指接入设备在发起802.1X认证失败后，能够再次发起MAC认证，使终端通过MAC认证接入。

MAC旁路认证属于802.1X认证，不属于MAC认证。与MAC认证相比，MAC旁路认证多出了802.1X认证环节，因此认证时间更长。

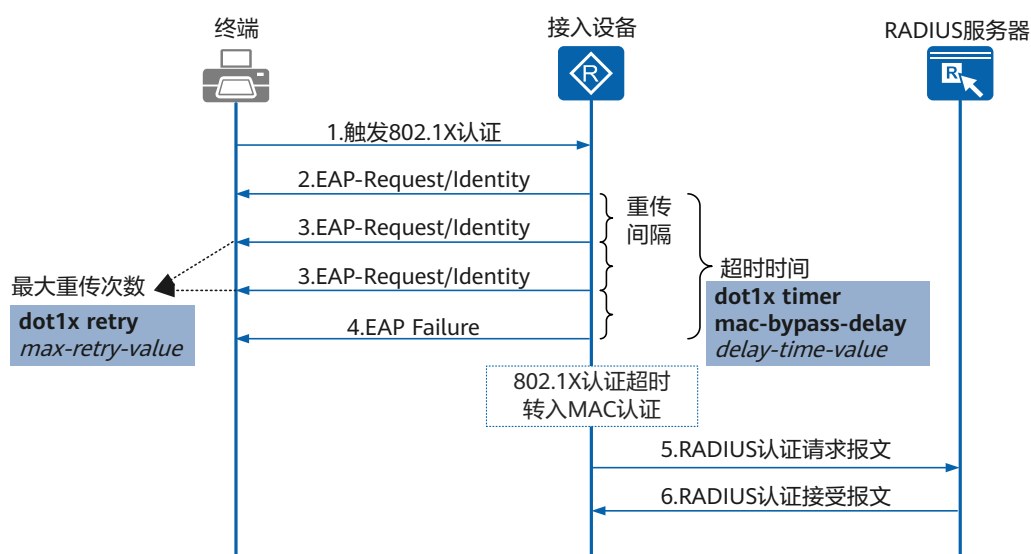
当接入设备接口下同时存在PC和打印机/传真机等哑终端时，推荐配置MAC旁路认证，从而先尝试对终端进行802.1X认证，认证失败后再尝试对终端进行MAC认证。

当接入设备接口下只存在打印机/传真机等哑终端时，推荐配置MAC认证，从而缩短认证时间。

认证流程

当接入设备接口下同时存在PC和打印机/传真机等哑终端时，如果仅配置802.1X认证，会导致打印机/传真机无法通过认证。此时可以通过MAC旁路认证功能，使不具备802.1X认证能力的哑终端能够通过MAC认证方式接入网络。MAC旁路认证流程如图3-34所示。

图 3-34 MAC 旁路认证流程



1. 在接入设备使能MAC旁路认证的接口上，接口收到用户终端的报文后，首先对该用户进行802.1X认证。
2. 接入设备向终端发送一个Identity类型的请求帧（EAP-Request/Identity）要求用户的客户端程序发送输入的用户名。
3. 如果在重传间隔内，接入设备未收到回应报文，会再次发送一个Identity类型的请求帧（EAP-Request/Identity）。
4. 接入设备不断重复步骤2，直至收到用户终端的回应。当重传次数达到最大重传次数后，如果接入设备仍未收到回应，则向用户发送EAP请求失败报文。
5. 此时，802.1X认证超时。接入设备将MAC认证用户名和密码发送到RADIUS服务器对该用户进行MAC认证。
6. RADIUS服务器将收到的MAC认证用户名和密码与本地保存的用户名和密码进行比对，如果相同，则MAC认证成功，并向设备发送RADIUS认证接受报文。

3.1.5.2 MAC 优先的 Portal 认证

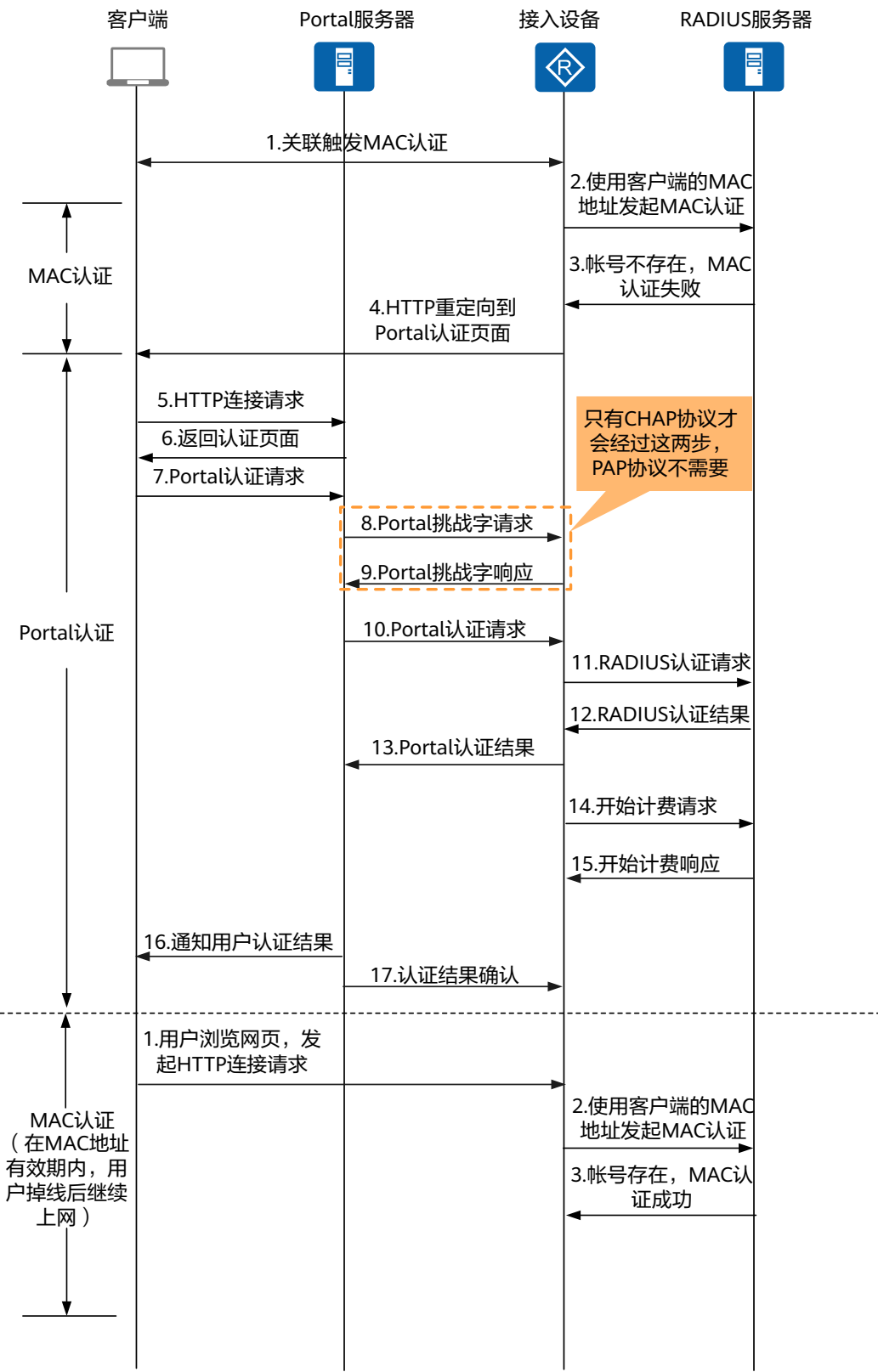
MAC优先的Portal认证是指用户进行Portal认证成功后，在一定时间内断开网络重新连接，能够直接通过MAC认证接入，无需输入用户名密码重新进行Portal认证。该功能需要在设备配置MAC+Portal的混合认证，同时在认证服务器上开启MAC优先的Portal认证功能并配置MAC地址有效时间，用户Portal认证成功后，在MAC地址有效时间内，可以通过MAC认证重新接入网络。

认证流程

如图3-35所示，客户端用户首次认证时，接入设备会把客户端的MAC地址发到RADIUS服务器进行认证，但由于RADIUS服务器未查找到MAC地址信息，导致认证失败，触发客户端用户进行Portal认证。认证成功后，RADIUS服务器会自动保存客户端的MAC地址。当客户端因无线信号不稳定或离开无线信号覆盖区域导致客户端掉线而重新尝试接入网络时，接入设备会把客户端的MAC地址发到RADIUS服务器进行认证。

- 如果客户端的MAC地址还保存在RADIUS服务器，则RADIUS服务器校验用户名和密码（用户名和密码均为MAC地址）后，直接进行授权，用户授权后即可直接访问网络，不需要再次输入用户名密码进行认证。
- 如果客户端的MAC地址在RADIUS服务器已经过期，则RADIUS服务器会删除保存的客户端MAC地址。MAC地址认证失败之后，接入设备会向客户端用户推送Portal认证页面。客户端用户输入帐号和密码完成身份认证。

图 3-35 认证流程图



3.1.6 NAC 逃生机制

当认证服务器Down、用户认证失败或者用户处于预连接状态，可以授予用户一定的网络访问权限。这种非认证成功状态的授权，称为逃生。对于不同的认证方式，有不同的逃生方案，有些逃生方案是共有的，有些逃生方案只有特定的认证方式才支持。

表 3-11 逃生方案

认证方式	触发事件	方案说明
802.1X	802.1X客户端无响应	执行命令 authentication event client-no-response action authorize ，配置用户在802.1X客户端无响应时的网络访问权限，详情请参见 3.5.2.1.3（可选）配置802.1X客户端无响应时的网络访问权限 。
	认证服务器Down	执行命令 authentication event authen-server-down action authorize ，配置用户在认证服务器Down时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。
	认证失败	执行命令 authentication event authen-fail action authorize ，配置用户在认证失败时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。
	预连接	执行命令 authentication event pre-authen action authorize ，配置用户在预连接时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。
Portal	认证服务器Down	执行命令 authentication event authen-server-down action authorize ，配置用户在认证服务器Down时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。
	认证失败	执行命令 authentication event authen-fail action authorize ，配置用户在认证失败时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。
	预连接	执行命令 authentication event pre-authen action authorize ，配置用户在预连接时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。
MAC	认证服务器Down	执行命令 authentication event authen-server-down action authorize ，配置用户在认证服务器Down时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。

认证方式	触发事件	方案说明
	认证失败	执行命令 authentication event authen-fail action authorize ，配置用户在认证失败时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。
	预连接	执行命令 authentication event pre-authen action authorize ，配置用户在预连接时的网络访问权限，详情请参见 3.5.3.3（可选）配置认证事件授权信息 。

用户授权顺序如下，设备会按照所处状态并依照优先级顺序依次检查是否配置了相应的权限，如果已配置，则按照配置的进行授权，如果未配置，则对下一优先级进行检查。

- 认证服务器Down时的授权顺序：认证服务器Down时的网络访问权限 ⇒ 用户在认证失败时的网络访问权限 ⇒ 用户在预连接阶段的网络访问权限 ⇒ 按照是否开启预连接功能进行授权处理。
- 用户在认证失败时的授权顺序：用户在认证失败时的网络访问权限 ⇒ 用户在预连接阶段的网络访问权限 ⇒ 按照是否开启预连接功能进行授权处理。
- 用户在预连接状态时的授权顺序：用户在预连接阶段的网络访问权限 ⇒ 按照是否开启预连接功能进行授权处理。
- 802.1X客户端无响应时的授权顺序：802.1X客户端无响应时的网络访问权限 ⇒ 用户在预连接阶段的网络访问权限 ⇒ 按照是否开启预连接功能进行授权处理。
- Portal服务器Down时的授权顺序：Portal服务器Down时的网络访问权限 ⇒ 维持Portal服务器Down前的访问权限。

3.1.7 NAC 认证逻辑流程

3.1.7.1 802.1X 认证逻辑流程

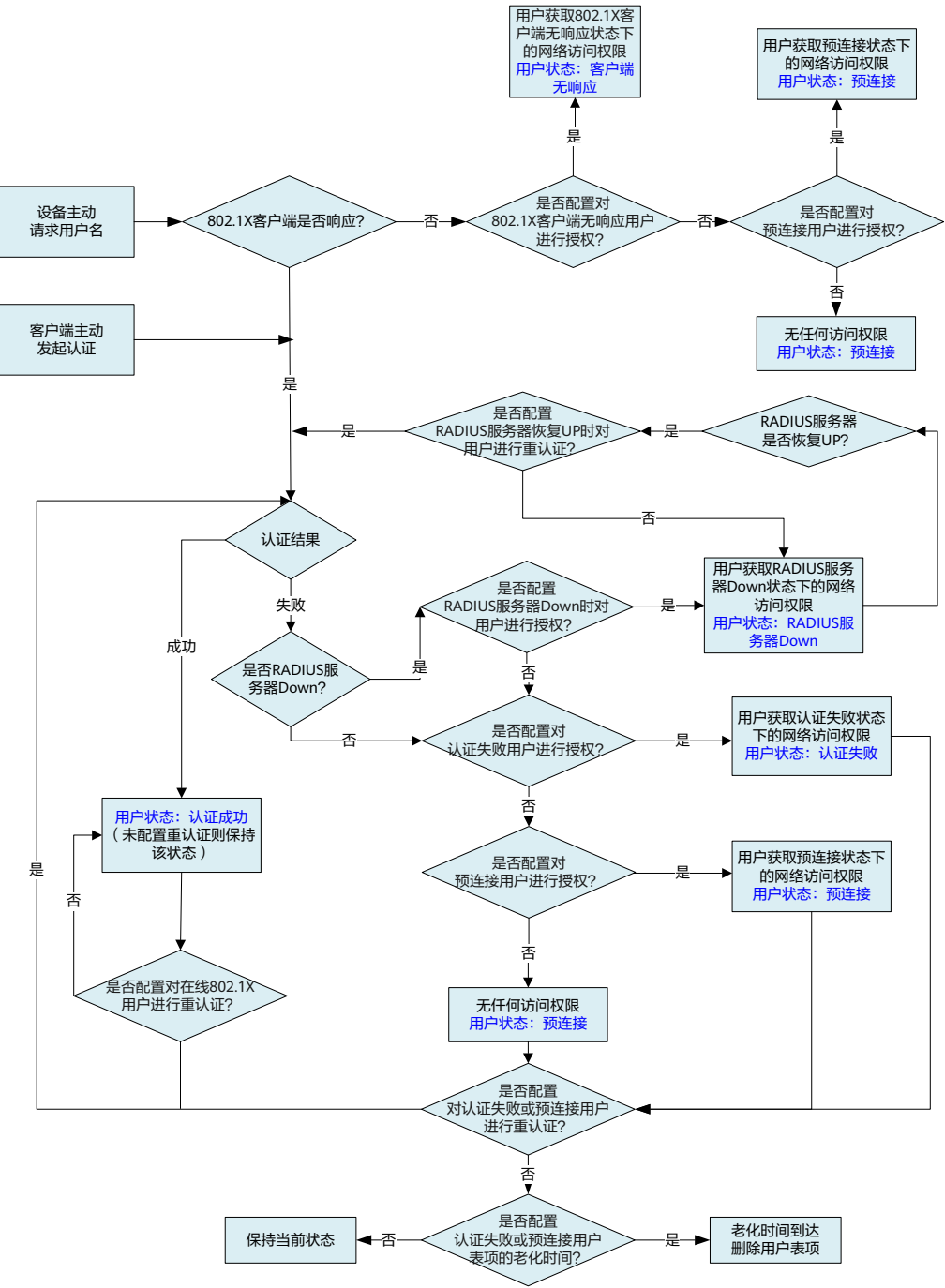
在用户进行802.1X认证的过程中，接入设备的处理逻辑如**图3-36**所示，此处以RADIUS认证方式为例进行说明。

1. 当设备主动向客户端请求用户名并且客户端无响应时，如果配置了802.1X客户端无响应的授权，则用户获取相应权限。否则，根据用户是否配置了预连接授权进行处理。
2. 当客户端主动发起认证，或客户端响应设备的认证请求时，如果RADIUS状态正常，用户认证成功授与完整权限，如果用户认证失败，则依次检查认证失败授权和预连接授权，并获取相应权限。
3. 当RADIUS服务器Down时，依次检查认证服务器Down时的网络访问权限，用户在认证失败时的网络访问权限，用户在预连接阶段的网络访问权限，按是否配置相应权限处理。
4. 如果配置了重认证，则按照重认证的触发机制对相应状态用户进行重认证。

说明

无线802.1X用户不支持认证事件授权，包括：802.1X客户端无响应授权，服务器Down授权，认证失败授权，预连接授权。

图 3-36 802.1X 认证设备处理逻辑



如需了解更为详细的信息，请参见：

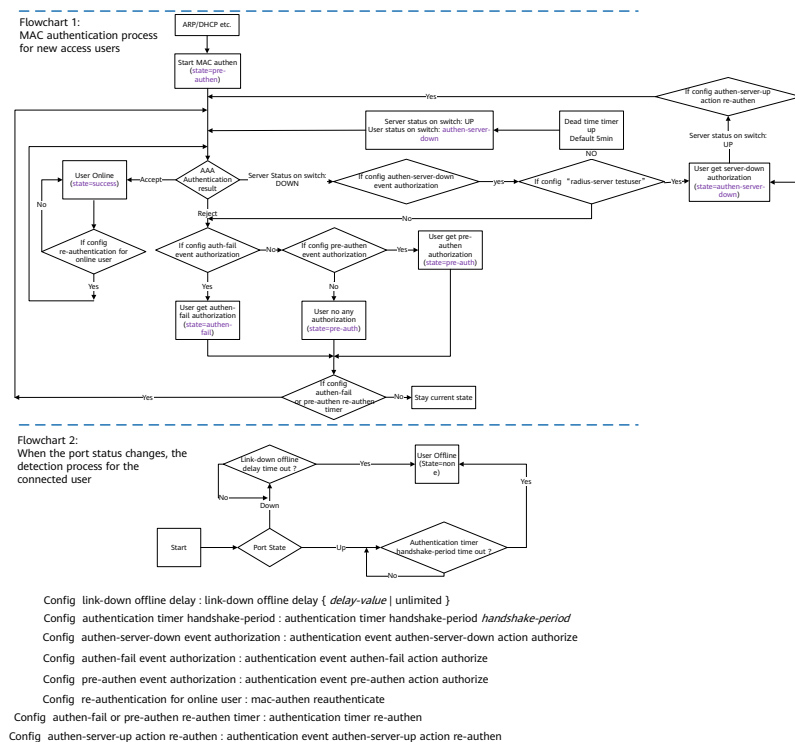
- [3.1.2.3 802.1X认证流程](#)
- [RADIUS服务器状态探测](#)
- [3.1.2.4 802.1X授权](#)
- [3.1.6 NAC逃生机制](#)

3.1.7.2 MAC 认证逻辑流程

在用户进行MAC认证的过程中，接入设备的处理逻辑如图3-37所示，此处以RADIUS认证方式为例进行说明。

1. 接入设备检测到新的MAC地址后，即触发对其进行MAC认证。
2. 接入设备向RADIUS服务器发送RADIUS认证请求报文对该终端进行MAC认证（详见**1.2.4.5 RADIUS服务器选择机制**和**3.1.3.2 MAC认证流程**）。
 - a. 如果MAC认证成功，则用户上线。
 - b. 如果MAC认证失败，且RADIUS服务器状态为Down（详见**1.2.4.6 RADIUS服务器状态探测**），设备依次检查其是否配置RADIUS服务器Down时对用户进行授权、是否配置对认证失败用户进行授权以及是否配置对预连接用户进行授权（详见**3.1.6 NAC逃生机制**），如果有，则终端获取相应权限；否则终端无任何网络访问权限。
 - c. 如果MAC认证失败，且RADIUS服务器状态为Up，设备依次检查是否配置对认证失败用户进行授权以及是否配置对预连接用户进行授权，如果有，则终端获取相应权限；否则终端无任何网络访问权限。
3. 对于异常认证状态下的用户，设备能够配置对其进行重认证，使其尽快获取正常的网络访问权限；对于MAC认证成功的用户，对其进行重认证也能保证终端的合法性（详见**3.1.3.4 MAC认证重认证**）。

图 3-37 接入设备的处理逻辑

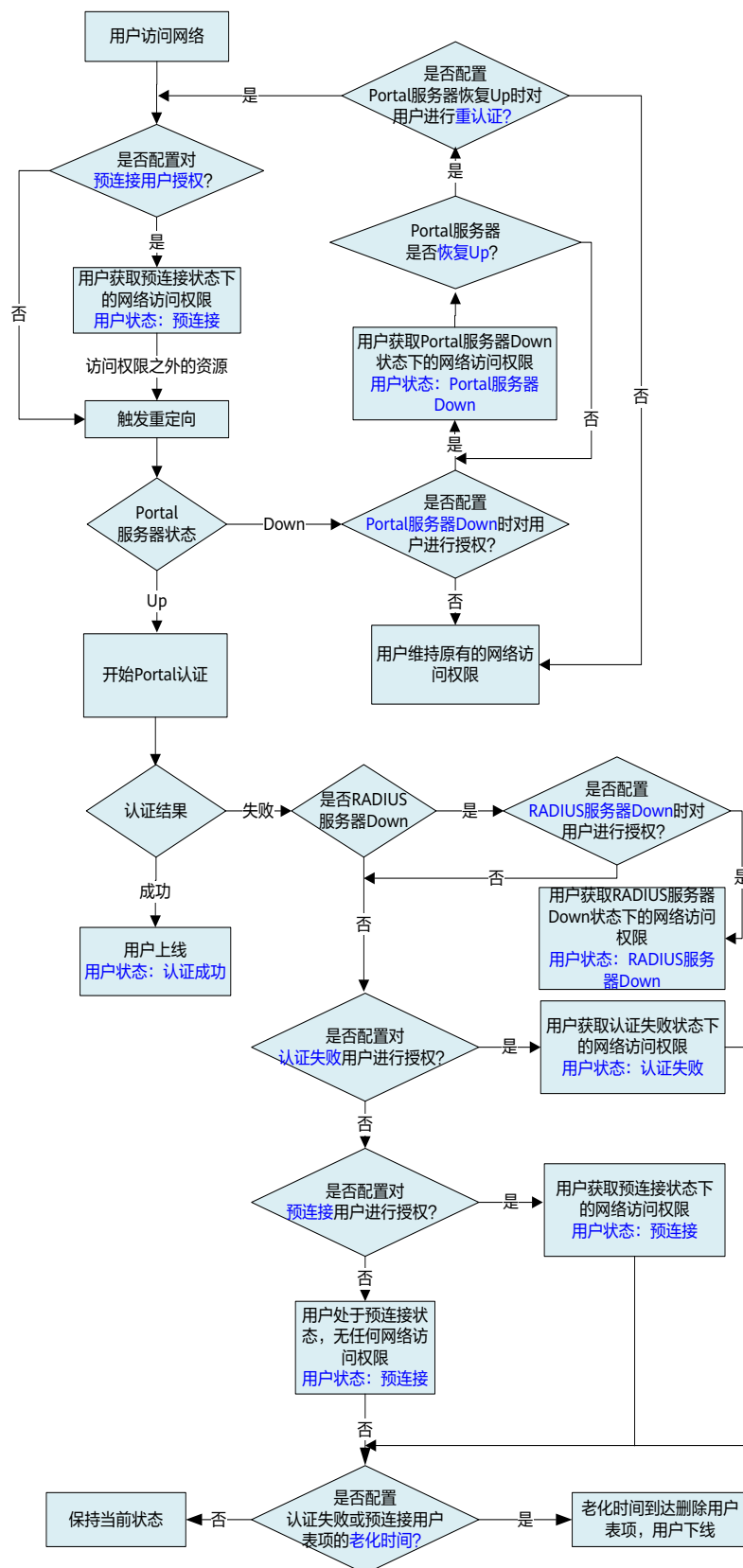


3.1.7.3 Portal 认证逻辑流程

在用户进行Portal认证的过程中，接入设备的处理逻辑如图3-38所示，此处以RADIUS认证方式为例进行说明。

1. 用户访问网络时，如果配置了预连接授权，则用户获取相应权限，用户访问权限之外的资源时，触发用户重定向到Portal认证网站；如果未配置预连接授权，则触发用户重定向到Portal认证网站。
2. 用户访问Portal认证网站，如果Portal服务器正常，则接入设备与RADIUS服务器进行Portal认证。如果Portal服务器Down，则检查Portal服务器Down时的网络访问权限，按是否配置相应权限处理，当配置了Portal服务器状由Down转变为Up时对用户进行重认证，按照重认证的触发机制对相应状态用户进行重认证。
3. Portal认证时，如果RADIUS服务器状态正常，则用户认证成功授与完整权限，如果用户认证失败，则依次检查认证失败授权和预连接授权，并获取相应权限。如果RADIUS服务器Down，则依次检查认证服务器Down时的网络访问权限、用户在认证失败时的网络访问权限、用户在预连接阶段的网络访问权限，按是否配置相应权限处理。

图 3-38 设备的处理逻辑



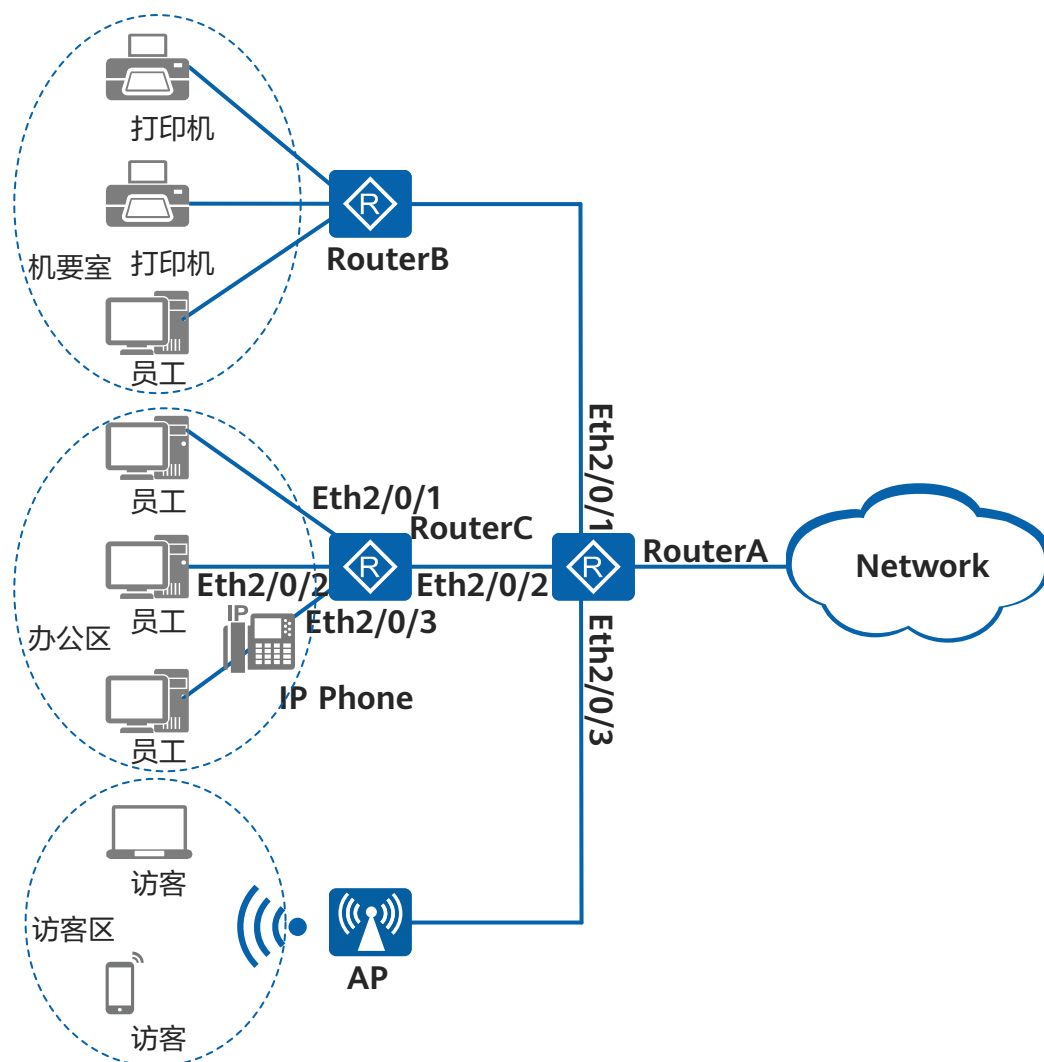
如需了解更为详细的信息，请参见：

- [3.1.4.4 Portal认证流程](#)
- [1.2.4.6 RADIUS服务器状态探测](#)
- [3.1.4.5 Portal认证授权](#)
- [3.1.6 NAC逃生机制](#)

3.2 NAC 应用场景

如图3-39所示，某企业中机要室通过RouterB连接到RouterA，办公区通过RouterC连接到RouterA，访客区通过AP连接到RouterA。为保证企业内部网络的安全性，需控制用户对网络的访问，只有通过认证的用户，才允许访问管理员授权的网络资源。

图 3-39 通过 NAC 控制企业用户访问网络示意图



机要室内终端类型较多而且打印机数量远大于员工数量，因此可在RouterA的接口Eth2/0/1上同时部署802.1X认证和MAC认证并且优先触发MAC认证，同时配置用户的接入模式为多用户单独认证接入（multi-authen）。

办公区内用户安全控制的要求较为严格，因此可在RouterC上仅连接PC的接口Eth2/0/1和Eth2/0/2上部署802.1X认证，同时配置用户的接入模式为单用户接入（single-terminal）；连接IP Phone和PC的接口Eth2/0/3上部署802.1X认证和MAC认证，同时配置用户的接入模式为单用户通过语音终端接入（single-voice-with-data）。

访客区用户流动性较大并且网络访问权限较低，因此可在RouterA的接口Eth2/0/3上部署Portal认证，同时配置用户的接入模式为多用户共享权限接入（multi-share）。

3.3 NAC 配置注意事项

涉及网元

表 3-12 本特性涉及网元

角色	产品	说明
AAA服务器	华为公司或第三方公司的AAA服务器产品。	负责对用户进行认证、计费 and 授权。
Portal服务器	华为公司或第三方公司的Portal服务器产品。	负责接收Portal客户端认证请求的服务器端系统，提供免费门户服务和基于Web认证的界面，与接入设备交互认证客户端的认证信息。 仅外置Portal认证方式需要该网元。

License 支持

NAC是设备的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

对于设备上的单板而言，仅8FE1GE单板支持此功能。

特性依赖和限制

- 通过命令**display access-user user-id**可以查看RADIUS服务器下发的流量限速参数值。如果RADIUS服务器上仅设置了流量限速的CIR值、没有设置其他流量限速参数值（CBS值或PBS值）时，接入设备会依据经验值校验得到其他参数值。
另外，接入设备对RADIUS服务器下发的流量限速参数进行校验后的取值与对QoS模板下发的流量限速参数进行校验后的取值有差异。
- 终端采用Portal认证或包含Portal认证的混合认证时，不支持为其授权VLAN。终端获取VLAN授权后，需要手动触发DHCP申请IP地址。

- 终端同时具有IPv4和IPv6地址时，仅IPv4地址能够进行用户探测，IPv4地址能够刷新IPv6地址对应的用户表项，IPv6地址不能刷新IPv4地址对应的用户表项。
- Portal认证场景中，存在用户仿冒IP地址进行认证的安全风险，建议用户配置IPSG和DHCP Snooping等防攻击功能来避免此安全风险。
- 由于手机终端不支持EAP终结方式（PAP和CHAP协议），故手机终端认证时不支持配置为802.1X+本地认证方式。笔记本电脑等终端也需要安装第三方客户端才能支持EAP终结方式。

3.4 NAC 缺省配置

802.1X 接入模板

系统自带1个名称为dot1x_access_profile的802.1X接入模板。设备上已创建的802.1X接入模板的缺省配置如表3-13所示。

表 3-13 802.1X 接入模板的缺省配置

参数	缺省值
802.1X用户认证方式	EAP认证
设备主动触发802.1X认证功能	已使能
对在线802.1X用户的重认证功能	未使能
认证请求报文的重传次数	2次
客户端认证超时时间	5秒
认证请求超时时间	30秒

MAC 接入模板

系统自带1个名称为mac_access_profile的MAC接入模板。设备上已创建的MAC接入模板的缺省配置如表3-14所示。

表 3-14 MAC 接入模板的缺省配置

参数	缺省值
MAC认证的用户名和密码形式	用户名和密码均为不带分隔符“-”的MAC地址
设备能够触发MAC认证的报文类型	DHCP/ARP/DHCPv6/ND报文
对在线MAC用户的重认证功能	未使能
对在线MAC用户重认证的周期	1800秒
收到DHCP续租报文后，对用户进行重认证的功能	未使能

Portal 接入模板

系统自带1个名称为portal_access_profile的Portal接入模板。设备上已创建的Portal接入模板的缺省配置如表3-15所示。

表 3-15 Portal 接入模板的缺省配置

参数	缺省值
使用的Portal服务器	未指定
Portal认证的源认证网段	对所有网段的用户都进行Portal认证。
用户下线探测周期	300秒
逃生授权（即在接入设备探测到Portal服务器Down时，授予用户的网络访问权限）	未指定
接入设备探测到Portal服务器的状态由Down转变为Up时，会对用户进行重认证的功能	未使能

认证模板

系统自带5个认证模板，名称分别为default_authen_profile、dot1x_authen_profile、mac_authen_profile、portal_authen_profile和dot1xmac_authen_profile。设备上已创建的认证模板的缺省配置如表3-16所示。

表 3-16 认证模板的缺省配置

参数	缺省值
接入模板类型及名称	未指定
用户接入模式	multi-authen
设备与在线用户的握手功能	使能
有线预连接用户或有线认证失败用户 的重认证周期	60秒

3.5 配置 NAC

3.5.1 NAC 配置流程

前置任务

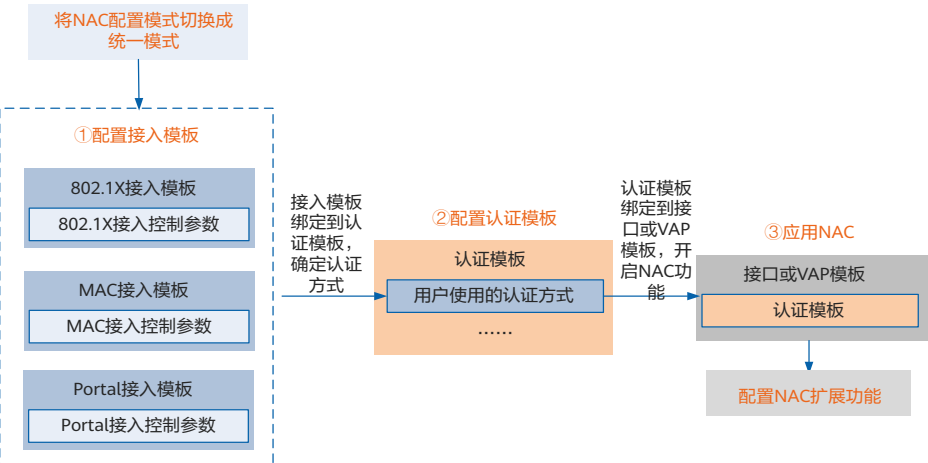
NAC仅为用户提供了多种网络接入控制协议，要完整的实现对用户身份验证、控制用户网络访问权限，还需要结合AAA的配置：

- 配置用户所属的域及其使用的AAA方案。
- 如果需要通过RADIUS或HWTACACS服务器进行认证，则应该在RADIUS或HWTACACS服务器上添加接入用户的用户名和密码。
- 如果需要本地认证，则应该在接入设备上手动添加接入用户的用户名和密码。

配置AAA客户端请参见[AAA配置](#)。

配置流程

图 3-40 NAC 配置流程



NAC 配置任务概览

认证方式	场景	对应任务
802.1X认证	在新建网络、用户集中、信息安全要求严格的场景，通过802.1X对用户进行接入控制。	请按照如下顺序依次配置： 1. 3.5.2.1 配置802.1X接入模板 2. 3.5.3 配置认证模板 3. 3.5.4 应用NAC
MAC认证	在打印机、传真机等哑终端接入认证的场景，通过MAC认证对用户进行接入控制。	请按照如下顺序依次配置： 1. 3.5.2.2 配置MAC接入模板 2. 3.5.3 配置认证模板 3. 3.5.4 应用NAC

认证方式	场景	对应任务
混合认证	为灵活地适应网络环境中的多种认证需求，设备支持多种认证方式同时部署。 配置哪几种认证方式混合，只需要在认证模板下绑定对应的接入模板。	请按照如下顺序依次配置： 1. 3.5.2 配置接入模板 2. 3.5.3 配置认证模板 3. 3.5.4 应用NAC

3.5.2 配置接入模板

3.5.2.1 配置 802.1X 接入模板

3.5.2.1.1 创建 802.1X 接入模板

背景信息

设备通过802.1X接入模板统一管理802.1X接入相关的配置。配置802.1X认证之前，首先需要创建802.1X接入模板。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**dot1x-access-profile name access-profile-name**，创建802.1X接入模板并进入802.1X接入模板视图。

缺省情况下，设备自带1个名称为dot1x_access_profile的802.1X接入模板。

说明

- 设备最多支持配置8个802.1X接入模板。其中，升级兼容转换的模板不占用配置规格。自带的1个802.1X接入模板（dot1x_access_profile）可以修改和应用，但不能删除。
- 删除某个802.1X接入模板时，需要保证该802.1X接入模板没有被任何认证模板绑定。

----结束

3.5.2.1.2 配置 802.1X 接入模板

背景信息

创建802.1X接入模板后，可以对其进行配置。用户可以根据客户端和服务器的认证方式的支持情况，并综合设备和服务器的处理能力选择合适的认证方式。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dot1x-access-profile name access-profile-name**，进入802.1X接入模板视图。

步骤3 执行命令**dot1x authentication-method { chap | pap | eap }**，配置802.1X用户的认证方式。

缺省情况下，802.1X用户认证方式为**eap**，即采用可扩展的认证协议EAP（Extensible Authentication Protocol）中继认证方式。

采用EAP终结还是EAP中继，将取决于RADIUS服务器的处理能力。如果RADIUS服务器的处理能力比较强，能够解析大量用户的EAP报文后再进行认证，可以采用EAP中继方式；如果RADIUS服务器处理能力不能够很好的同时解析大量EAP报文并完成认证，建议采用EAP终结方式，由设备帮助RADIUS服务器完成前期的EAP解析工作。在配置对认证报文的处理方式时，务必保证客户端与服务器均支持该种方式，否则用户无法通过认证。

说明

- 只有采用RADIUS认证时，802.1X用户的认证方式才可以配置为EAP中继方式。
- 采用AAA本地认证时，802.1X用户的认证方式只能配置为EAP终结方式。
- 由于手机终端不支持EAP终结方式（PAP和CHAP协议），故手机终端认证时不支持配置为802.1X+本地认证方式。笔记本电脑等终端也需要安装第三方客户端才能支持EAP终结方式。
- 如果802.1X客户端采用MD5加密方式，则设备端用户的认证方式可配置为EAP或CHAP方式；如果802.1X客户端采用PEAP认证方式，则设备端用户的认证方式可配置为EAP。
- 无线场景中，如果安全策略模板配置为WPA或WPA2认证方式，802.1X认证不支持认证前域授权。
- 当接口下已经有802.1X用户在线时，在接口绑定的802.1X接入模板下修改用户认证方式，如果是EAP终结和EAP中继两种方式之间切换，已经在线的用户会下线，如果是EAP终结之间的chap和pap之间切换，用户不会下线。

步骤4 （可选）执行命令**authentication trigger-condition { dhcp | arp } ***，配置能够触发802.1X认证的报文类型。

缺省情况下，DHCP/ARP报文均能够触发802.1X认证。

步骤5 （可选）执行命令**dot1x unicast-trigger**，使能单播报文触发802.1X认证功能。

缺省情况下，未使能单播报文触发802.1X认证功能。

步骤6 （可选）执行命令**dot1x port-control { auto | authorized-force | unauthorized-force }**，配置接口的授权状态。

缺省情况下，接口的授权状态为**auto**。

步骤7 （可选）执行命令**dot1x eap-notify-packet eap-code code-number data-type type-number**，配置向802.1X用户回应EAP报文类型值功能。

缺省情况下，设备不向802.1X用户回应EAP报文类型值。

说明

当采用H3C iMC作为RADIUS服务器时，设备上需要配置命令**dot1x eap-notify-packet eap-code 10 data-type 25**。

步骤8 （可选）执行命令**dot1x trigger dhcp-binding**，配置静态IP用户802.1X认证成功后或处于预连接阶段时，设备自动生成对应的DHCP Snooping绑定表。

缺省情况下，静态IP用户802.1X认证成功后或处于预连接阶段时，设备不会自动生成对应的DHCP Snooping绑定表。

步骤9 （可选）执行命令**dot1x receive-packet vlan-ignore**，使能认证设备接收EAP报文时的VLAN替换功能。

缺省情况下，未使能认证设备接收EAP报文时的VLAN替换功能。

----结束

3.5.2.1.3 （可选）配置 802.1X 客户端无响应时的网络访问权限

背景信息

802.1X客户端无响应会造成用户无法通过认证，导致用户无任何网络访问权限。但是，某些用户在认证成功之前，可能需要一些基本的网络访问权限，以完成下载客户端、更新病毒库等需求。此时，可以通过配置用户在802.1X客户端无响应时的网络访问权限，使用户可以访问特定的网络资源。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置授权参数

- VLAN
需在设备上配置VLAN及VLAN内的网络资源。
- 业务方案
需在设备上配置业务方案，详细配置步骤请参见（可选）配置业务方案。
- 用户组
 - a. 执行命令**user-group group-name [group-index group-index]**，创建用户组并进入用户组视图。
 - b. 执行命令**acl-id acl-number**，在用户组下绑定ACL。
缺省情况下，用户组下未绑定ACL。

说明

- 执行该命令之前，需确保已使用命令**acl**或**acl name**创建了ACL；并使用命令**rule**配置相应的ACL规则。
- 用户组内有用户在线的情况下，与该用户组绑定的ACL不允许在系统视图下直接修改或删除。
- c. 执行命令**user-vlan vlan-id**，配置用户组VLAN。
缺省情况下，未配置用户组VLAN。

说明

执行该命令之前，需确保已使用命令**vlan**创建了VLAN。

- d. 执行命令**remark { 8021p 8021p-value | dscp dscp-value | exp exp-value | lp lp-value } ***，配置用户组优先级。

缺省情况下，未配置用户组优先级。

- e. 执行命令**quit**，返回到系统视图。

步骤3 执行命令**dot1x-access-profile name access-profile-name**，进入802.1X接入模板视图。

步骤4 执行命令**authentication event client-no-response action authorize { service-scheme service-scheme-name | user-group user-group-name | vlan vlan-id }**，配置用户在802.1X客户端无响应时的网络访问权限。

缺省情况下，未配置用户在802.1X客户端无响应时的网络访问权限。

----结束

3.5.2.1.4（可选）配置对在线 802.1X 用户进行重认证

背景信息

若管理员在认证服务器上修改了某一用户的访问权限、授权属性等参数，此时如果用户已经在线，则需要及时对该用户进行重认证以确保用户的合法性。

配置对在线802.1X用户进行重认证功能后，设备会把保存的在线用户的认证参数（用户上线后，设备上会保存该用户的认证信息）发送到认证服务器进行重认证，若认证服务器上用户的认证信息没有变化，则用户正常在线；若用户的认证信息已更改，则用户将会被下线，此后用户需要重新进行认证。

对802.1X用户进行重认证的方式有两种：

- 对使用指定802.1X接入模板的用户周期性自动进行重认证。

说明

配置该功能后，会导致802.1X认证的日志信息较多。

- 手动对指定MAC地址的用户进行单次重认证。

设备与某服务器对接进行重认证时，如果服务器回复重认证拒绝消息导致已在线用户下线，则建议服务器侧定位重认证失败原因或者设备去使能重认证功能。

操作步骤

- 周期性自动重认证
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**dot1x-access-profile name access-profile-name**，进入802.1X接入模板视图。
 - c. 执行命令**dot1x reauthenticate**，配置对在线802.1X用户进行重认证的功能。

缺省情况下，未配置对在线802.1X用户进行重认证的功能。
 - d. （可选）执行命令**dot1x timer reauthenticate-period reauthenticate-period-value**，配置对在线802.1X用户进行重认证的周期。

缺省情况下，对在线802.1X用户进行重认证的周期为3600秒。

说明

一般情况下，重认证周期建议采用默认值。如果用户授权时需要下发多条ACL，为提高设备处理性能，建议关闭重认证功能或将重认证周期调长。

在采用远端认证、授权的情况下，如果配置的重认证周期过短则可能导致CPU占用率较高。

当用户数较多时，为减少对设备性能的影响，用户进行重认证的周期可能大于配置的重认证的周期。

客户端认证超时时间与认证请求的重传次数（通过命令**dot1x retry**配置）的乘积不能大于110。

- 手动单次重认证
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**dot1x reauthenticate mac-address mac-address**，手动对指定MAC地址的用户进行单次重认证。

----结束

3.5.2.1.5（可选）配置 802.1X 定时器

背景信息

802.1X认证通过定时器控制EAP-Request/Identity报文和EAP-Request/MD5 Challenge的重传机制。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dot1x timer tx-period tx-period-value**，配置发送802.1X认证请求报文的时间间隔。

缺省情况下，发送802.1X认证请求的时间间隔为30秒。

步骤3 执行命令**dot1x timer mac-bypass-delay delay-time-value**，配置802.1X认证开始后经过多长时间仍未认证成功则进行MAC认证。

缺省情况下，802.1X认证开始后经过30秒仍未认证成功则进行MAC认证。

步骤4 执行命令**dot1x-access-profile name access-profile-name**，进入802.1X接入模板视图。

步骤5 执行命令**dot1x timer client-timeout client-timeout-value**，配置802.1X客户端认证超时定时器。

缺省情况下，802.1X客户端认证超时定时器默认开启、时长为5秒。

步骤6 执行命令**dot1x retry max-retry-value**，配置向802.1X用户发送认证请求报文的重传次数。

缺省情况下，向802.1X用户发送认证请求报文的重传次数为2次。

----结束

3.5.2.1.6 （可选）配置动态 VLAN 功能

背景信息

在接口上执行**dynamic-macvlan enable**命令，在接口通过802.1X/MAC认证之后，无论用户从哪个接口接入，上送CPU处理的报文会被打上RADIUS服务器下发的VLAN属性，使设备的MAC地址和VLAN绑定，不受接口配置的PVID影响。

说明

仅AR720、AR730支持此功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface gigabitethernet *interface-number***，进入GE接口视图。

步骤3 执行命令**dynamic-macvlan enable**，使能动态VLAN功能。

缺省情况下，未使能动态VLAN功能。

说明

- 本命令只支持在设备面板二层口上进行配置。
- 接口类型必须是hybrid untagged类型。
- 使能动态VLAN功能后的接口仅支持三层业务。
- 如果当前接口已经应用了authentication-profile认证模板，需要先解除绑定authentication-profile认证模板，然后在接口下使能**dynamic-macvlan enable**命令。
- 对于不支持动态VLAN功能的款型，如果授权的VLAN和端口配置的VLAN不同，会出现业务不通。
- 配置动态VLAN后，必须配置认证前域授权VLAN，否则会导致终端获取不到动态VLAN的地址。

----结束

3.5.2.1.7 检查 802.1X 接入模板配置结果

背景信息

完成802.1X接入模板的配置后，执行以下命令查看配置信息。

操作步骤

- 执行命令**display dot1x-access-profile configuration [name *access-profile-name*]**，查看802.1X接入模板的配置信息。

----结束

3.5.2.2 配置 MAC 接入模板

3.5.2.2.1 创建 MAC 接入模板

背景信息

设备通过MAC接入模板统一管理MAC用户接入相关的配置。配置MAC认证之前，首先需要创建MAC接入模板。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**mac-access-profile name access-profile-name**，创建MAC接入模板并进入MAC接入模板视图。

缺省情况下，设备自带1个名称为mac_access_profile的MAC接入模板。

说明

- 设备最多支持配置8个MAC接入模板。其中，升级兼容转换的模板不占用配置规格。自带的1个MAC接入模板（mac_access_profile）可以修改和应用，但不能删除。
- 删除某个MAC接入模板时，需要保证该MAC接入模板没有被任何认证模板绑定。

----结束

3.5.2.2.2 配置 MAC 接入模板

背景信息

创建MAC接入模板后，可以对其进行配置。用户可以综合设备、服务器和安全性等选择合适的认证方式。MAC认证过程中，不需要手动输入用户名和密码，但需要在设备上配置MAC认证的用户名类型格式和密码。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**mac-access-profile name access-profile-name**，进入MAC接入模板视图。

步骤3 执行命令**mac-authen authentication-method { chap | pap }**，配置MAC认证用户的认证方式。

缺省情况下，MAC认证用户认证方式为PAP认证。

步骤4 执行命令**mac-authen username { fixed username [password cipher password] | macaddress [format { with-hyphen [normal] | without-hyphen } [uppercase] [password cipher password] }**，配置MAC认证用户采用的用户名形式。

缺省情况下，MAC认证的用户名和密码均为不带分隔符“-”的MAC地址。

说明

- 配置MAC认证的用户名形式时，需要确保认证服务器支持该用户名形式。

步骤5 （可选）执行命令**authentication trigger-condition { dhcp | arp } ***，配置能够触发MAC认证的报文类型。

缺省情况下，DHCP/ARP报文均能够触发MAC认证。

步骤6 （可选）执行命令**mac-authen permit mac-address mac-address mask { mask | mask-length }**，配置设备允许用户进行MAC认证的MAC地址段。

缺省情况下，未配置允许用户进行认证的MAC地址段。

说明

仅VLANIF接口上线的MAC认证用户支持该功能。

步骤7 （可选）执行命令**mac-authen trigger dhcp-binding**，配置静态IP用户MAC认证成功或处于预连接阶段时，设备自动生成对应的DHCP Snooping绑定表。

缺省情况下，静态IP用户MAC认证成功或处于预连接阶段时，设备不会自动生成对应的DHCP Snooping绑定表。

----结束

3.5.2.2.3 （可选）配置对在线 MAC 用户进行重认证

背景信息

若管理员在认证服务器上修改了某一用户的访问权限、授权属性等参数，此时如果用户已经在线，则需要及时对该用户进行重认证以确保用户的合法性。

配置对在线MAC用户进行重认证功能后，设备会把保存的在线用户的认证参数（用户上线后，设备上会保存有该用户的认证信息）发送到认证服务器进行重认证，若认证服务器上用户的认证信息没有变化，则用户正常在线；若用户的认证信息已更改，则用户将会被下线，此后用户需要重新进行认证。

对MAC用户进行重认证的方式：

- 对使用指定MAC接入模板的用户周期性自动进行重认证。

说明

配置该功能后，会导致MAC认证的日志信息较多。

- 接收到MAC用户的DHCP续租报文后，对用户进行重认证。该项必须保证设备已经配置了通过DHCP报文触发MAC认证的功能。
- 手动对指定MAC地址的用户进行单次重认证。

操作步骤

- 周期性自动重认证
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**mac-access-profile name access-profile-name**，进入MAC接入模板视图。
 - c. 执行命令**mac-authen reauthenticate**，使能对在线MAC用户进行重认证的功能。

缺省情况下，未使能对在线MAC用户进行重认证的功能。
 - d. （可选）执行命令**mac-authen timer reauthenticate-period reauthenticate-period-value**，配置对在线MAC用户进行重认证的周期。

缺省情况下，对在线MAC用户进行重认证的周期为1800秒。

说明

一般情况下，重认证周期建议采用默认值。如果用户授权时需要下发多条ACL，为提高设备处理性能，建议关闭重认证功能或将重认证周期调长。

在采用远端认证、授权的情况下，如果配置的重认证周期过短则可能导致CPU占用率较高。

当用户数较多时，为减少对设备性能的影响，用户进行重认证的周期可能大于配置的重认证的周期。

客户端认证超时时间与认证请求的重传次数（通过命令**dot1x retry**配置）的乘积不能大于110。

- 手动单次重认证
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**mac-authen reauthenticate mac-address mac-address**，手动对指定MAC地址的用户进行单次重认证。

----结束

3.5.2.2.4（可选）配置动态 VLAN 功能

背景信息

在接口上执行**dynamic-macvlan enable**命令，在接口通过802.1X/MAC认证之后，无论用户从哪个接口接入，上送CPU处理的报文会被打上RADIUS服务器下发的VLAN属性，使设备的MAC地址和VLAN绑定，不受接口配置的PVID影响。

说明

仅AR720、AR730支持此功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface gigabitethernet interface-number**，进入GE接口视图。

步骤3 执行命令**dynamic-macvlan enable**，使能动态VLAN功能。

缺省情况下，未使能动态VLAN功能。

说明

- 本命令只支持在设备面板二层口上进行配置。
- 接口类型必须是hybrid untagged类型。
- 使能动态VLAN功能后的接口仅支持三层业务。
- 如果当前接口已经应用了authentication-profile认证模板，需要先解除绑定authentication-profile认证模板，然后在接口下使能**dynamic-macvlan enable**命令。
- 对于不支持动态VLAN功能的款型，如果授权的VLAN和端口配置的VLAN不同，会出现业务不通。
- 配置动态VLAN后，必须配置认证前域授权VLAN，否则会导致终端获取不到动态VLAN的地址。

----结束

3.5.2.2.5 检查 MAC 接入模板配置结果

背景信息

完成MAC接入模板的配置后，执行以下命令查看配置信息。

操作步骤

- 执行命令**display mac-access-profile configuration [name access-profile-name]**，查看MAC接入模板的配置信息。

----结束

3.5.3 配置认证模板

3.5.3.1 创建认证模板

背景信息

NAC能够实现对用户进行接入控制，为便于管理员配置NAC的相关功能，设备使用认证模板统一管理NAC的配置信息。通过配置认证模板下的参数（例如：配置认证模板下绑定的接入模板，确定认证模板的认证方式；之后应用该认证模板的接口或VAP模板采用以上认证方式对用户做认证），实现对不同的用户进行不同的接入控制。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**authentication-profile name authentication-profile-name**，创建认证模板并进入认证模板视图。

缺省情况下，设备自带6个认证模板，名称分别为default_authen_profile、dot1x_authen_profile、mac_authen_profile、portal_authen_profile、dot1xmac_authen_profile和multi_authen_profile。

说明

- 认证模板的规格为8个。自带的认证模板default_authen_profile和升级兼容转换的认证模板不占用规格。自带的6个认证模板（default_authen_profile、dot1x_authen_profile、mac_authen_profile、portal_authen_profile、multi_authen_profile和dot1xmac_authen_profile）可以修改和应用，但不能被删除。
- 删除某个认证模板时，需要保证该认证模板没有被绑定到任何接口或VAP模板。可以通过命令**display authentication-profile configuration**，查看认证模板是否被绑定到接口或VAP模板下。

----结束

3.5.3.2 配置认证模板

背景信息

NAC包括802.1X、MAC认证方式。接口或VAP模板下用户使用的认证方式，是由认证模板绑定的接入模板决定的。例如，管理员如果希望使用MAC认证对从某VAP模板上线的用户进行控制管理，则该VAP模板下应用的认证模板需要绑定MAC接入模板。

另外，为了灵活地适应网络环境中的多种认证需求，设备支持在接入用户的接口或VAP模板上部署多种认证方式，即混合认证。此时，就需要在认证模板上绑定多种接入模板。

前置任务

完成接入模板的配置，其中：

- 802.1X接入模板的配置请参见[3.5.2.1 配置802.1X接入模板](#)。
- MAC接入模板的配置请参见[3.5.2.2 配置MAC接入模板](#)。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**authentication-profile name authentication-profile-name**，进入认证模板视图。

步骤3 配置用户使用的认证方式。

- 802.1X认证

执行命令**dot1x-access-profile access-profile-name**，配置认证模板绑定的802.1X接入模板。

缺省情况下，认证模板没有绑定802.1X接入模板。

- MAC认证

执行命令**mac-access-profile access-profile-name**，配置认证模板绑定的MAC接入模板。

缺省情况下，认证模板没有绑定MAC接入模板。

- Portal认证

执行命令**portal-access-profile access-profile-name**，配置认证模板绑定的Portal接入模板。

缺省情况下，认证模板没有绑定Portal接入模板。

- 混合认证

配置哪几种认证方式混合，只需要在认证模板下绑定对应的接入模板。认证顺序为MAC认证、802.1X认证和Portal认证，但是配置多种认证方式包括Portal认证时，设备永远最后进行Portal认证。

另外，对于无法安装和使用802.1X客户端软件的终端，例如打印机等，可以使能MAC旁路认证功能。之后，用户首先会进行802.1X认证，一旦用户名请求失败，则设备会对用户启动MAC认证流程。

以配置MAC旁路认证为例，配置步骤如下：

- a. 执行命令**mac-access-profile access-profile-name**，配置认证模板绑定的MAC接入模板。

缺省情况下，认证模板没有绑定MAC接入模板。

- b. 执行命令**dot1x-access-profile access-profile-name**，配置认证模板绑定的802.1X接入模板。

缺省情况下，认证模板没有绑定802.1X接入模板。

- c. 执行命令**authentication dot1x-mac-bypass**，使能MAC旁路认证功能。

缺省情况下，未使能MAC旁路认证功能。

说明

部署混合认证时，需要注意以下几点：

- 一个认证模板最多支持绑定一个802.1X接入模板、一个MAC接入模板和一个Portal接入模板。
- 配置混合认证后，默认允许用户能够使用多种认证方式。例如：用户MAC认证成功后，访问网页时，不会重定向到Portal认证页面，但是，如果用户直接输入Portal认证网页地址，则可以进行Portal认证，认证成功后，能够获取Portal认证用户的网络访问权限。如果希望用户以一种方式认证成功后不再以其他方式进行认证，可以通过命令 **authentication single-access**，配置设备仅允许用户通过一种方式的认证。

步骤4 （可选）执行命令**authentication mode { single-terminal | single-voice-with-data | multi-share | multi-authen [max-user max-user-number [dot1x | mac-authen | portal | none] *] }**，配置接口的用户接入模式或接口的接入认证模式为**multi-authen**时允许接入的最大用户数。

缺省情况下，接口的接入认证模式为**multi-authen**。

步骤5 （可选）执行命令**authentication ip-address in-accounting-start**，开启在计费开始报文中携带用户IP地址功能。

缺省情况下，计费开始报文中携带用户IP地址功能处于关闭状态。

该命令仅对802.1X认证和MAC认证用户生效。Portal认证的计费开始报文中默认已携带用户IP地址。

步骤6 （可选）执行命令**authentication ip-conflict-check enable**，开启设备对客户端IP地址作冲突检测功能。

缺省情况下，设备对客户端IP地址作冲突检测。

步骤7 （可选）执行命令**authentication roam pre-authen mac-authen enable**，开启对漫游用户进行MAC认证功能。

缺省情况下，对漫游用户进行MAC认证功能处于关闭状态。

步骤8 （可选）配置设备与预连接用户以及已授权用户之间进行握手功能。

1. 执行命令**authentication handshake**，使能设备与预连接用户以及已授权用户之间进行握手功能。

缺省情况下，已使能设备与预连接用户以及已授权用户之间进行握手功能。

2. 执行命令**authentication timer handshake-period handshake-period**，配置设备与预连接用户以及已授权用户之间的握手周期。

缺省情况下，设备与预连接用户以及已授权用户之间的握手周期为300秒。

步骤9 （可选）执行命令**access-domain domain-name [dot1x | mac-authen | portal] * [force]**，配置用户的默认域或强制域。

缺省情况下，认证模板中未配置用户的默认域或强制域，用户默认使用全局默认域“default”。

说明

- 不指定该参数**force**时，配置的为默认域；指定参数**force**时，配置的为强制域。同时配置用户默认域和强制域时，用户在强制域中进行认证。
- 不指定参数**dot1x**、**mac-authen**或**portal**时，则配置的域对使用认证模板的所有接入认证用户都生效；指定参数**dot1x**、**mac-authen**或**portal**时，则配置的域仅对指定的用户生效。
- 对于MAC认证用户，可以在系统视图下执行命令**domain mac-authen force**配置MAC认证用户所使用的认证域。**access-domain mac-authen**和**domain mac-authen force**命令都配置时，**domain mac-authen force**命令优先生效。

步骤10 （可选）执行命令**link-down offline delay { delay-value | unlimited }**，配置接口链路故障时，用户延时下线的时间间隔。

缺省情况下，接口链路故障时，用户延时下线的时间间隔为10秒。

配置为0，表示接口链路故障时，用户立即下线；配置为**unlimited**，表示接口链路故障时，用户不下线。

步骤11 （可选）执行命令**authentication termination-action reauthenticate**，配置设备在RADIUS服务器通过Session-Timeout属性下发的超时时间到达后对用户进行重认证。

缺省情况下，未配置设备在RADIUS服务器通过Session-Timeout属性下发的超时时间到达后对用户进行重认证。

步骤12 （可选）执行命令**authentication arp-reply trigger**，开启ARP响应报文触发认证功能。

缺省情况下，已开启ARP响应报文触发认证功能。

步骤13 （可选）执行命令**authentication { roam-accounting | update-ip-accounting } * enable**，配置漫游和地址更新时发送计费报文。

缺省情况下，漫游和地址更新时发送计费报文。

对于多链路计费用户，使能漫游计费功能后，还需要通过命令，使能漫游计费时使用更新计费会话方式。

----结束

3.5.3.3 （可选）配置认证事件授权信息

背景信息

当用户在预连接状态或者认证失败状态时，用户将无任何网络访问权限。

为满足这些用户的基本网络访问需求，比如更新病毒库、下载客户端等，可在设备上配置认证事件授权信息，之后，设备即会根据用户所处的认证阶段为其授权。

说明

不支持为在线Portal用户授权VLAN。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置授权参数

用户在预连接、认证失败或认证服务器Down时，支持通过VLAN和业务方案授权。

- VLAN
需在设备上配置VLAN及VLAN内的网络资源。
- 业务方案
需在设备上配置业务方案，详细配置步骤请参见（可选）配置业务方案。

步骤3 执行命令**authentication-profile name authentication-profile-name**，进入认证模板视图。

步骤4 配置授权信息。

- 执行命令**authentication event pre-authen action authorize { vlan vlan-id | service-scheme service-scheme-name }**，配置用户在预连接阶段的网络访问权限。
- 执行命令**authentication event authen-fail action authorize { vlan vlan-id | service-scheme service-scheme-name } [response-fail]**，配置用户在认证失败时的网络访问权限。
- 执行命令**authentication event authen-server-down action authorize { vlan vlan-id | service-scheme service-scheme-name } [response-fail]**，配置用户在认证服务器Down时的网络访问权限。

缺省情况下，未配置认证事件授权信息。

说明

如果没有配置认证失败或认证服务器Down时用户的网络访问权限，当用户认证失败后，用户仍保持在预连接状态，拥有预连接用户的网络访问权限。

通过VLAN对用户进行授权，不适用于通过VLANIF接口接入的认证用户。

对于有线用户进行802.1X认证，当RADIUS服务器Down时，某些客户端新上线时无法拥有逃生权限，例如新上线的Windows客户端收到设备回应的Success报文时未收到与RADIUS服务器的认证交互报文，导致认证失败，无法上线。目前如下客户端新上线时可以拥有逃生权限：使用EAP-MD5和PEAP协议的H3C iNode客户端、使用EAP-FAST和PEAP协议的Cisco AnyConnect客户端。对于Windows客户端，以Windows 7为例，需选择“本地连接 > 属性 > 身份验证 > 回滚到未经授权的网路”。

如果配置了认证服务器Down的授权，设备探测到认证服务器Down后，用户认证失败并授予用户认证服务器Down的授权，并将用户加入到认证服务器Down的表项；如果没有配置认证服务器Down的授权，设备探测到认证服务器Down后，用户认证失败并会授予用户认证失败的授权，并将用户加入到认证失败的表项。

如果只配置了用户在认证失败时的授权，802.1X认证失败后会授予用户认证失败的授权，有线用户默认等待60s后进行重认证，如果客户端认证失败后静默，不回应设备的Request/Identity报文，而设备又没有配置802.1X客户端无响应时的授权和预连接授权，设备就会将用户下线。

用户授权顺序如下，设备会按照所处状态并依照优先级顺序依次检查是否配置了相应的权限，如果已配置，则按照配置的进行授权，如果未配置，则对下一优先级进行检查。

- 认证服务器Down时的授权顺序：认证服务器Down时的网络访问权限 ⇒ 用户在认证失败时的网络访问权限 ⇒ 用户在预连接阶段的网络访问权限 ⇒ 按照是否开启预连接功能进行授权处理。
- 用户在认证失败时的授权顺序：用户在认证失败时的网络访问权限 ⇒ 用户在预连接阶段的网络访问权限 ⇒ 按照是否开启预连接功能进行授权处理。
- 用户在预连接状态时的授权顺序：用户在预连接阶段的网络访问权限 ⇒ 按照是否开启预连接功能进行授权处理。
- 802.1X客户端无响应时的授权顺序：802.1X客户端无响应时的网络访问权限 ⇒ 用户在预连接阶段的网络访问权限 ⇒ 按照是否开启预连接功能进行授权处理。

步骤5 （可选）配置用户表项的老化时间。

- 执行命令**authentication timer pre-authen-aging aging-time**，配置预连接用户表项的老化时间。
缺省情况下，预连接用户表项的老化时间是23小时。
- 执行命令**authentication timer authen-fail-aging aging-time**，配置认证失败用户表项的老化时间。
缺省情况下，认证失败用户表项的老化时间是23小时。

 说明

认证服务器Down表项和认证失败表项的老化时间都是通过命令**authentication timer authen-fail-aging aging-time**配置。

----结束

3.5.3.4 （可选）配置用户的免认证授权信息

背景信息

用户认证成功之前，为满足用户基本的网络访问需求，譬如下载802.1X客户端、更新病毒库等，需要用户免认证就能获取部分网络访问权限。用户免认证的授权信息使用免认证规则模板统一管理，通过在模板中定义一些网络访问规则，确定用户免认证时可以获取的网络访问权限。免认证规则模板配置完成后，需要绑定到认证模板下，之后使用该认证模板的用户即可获取免认证授权信息。

 说明

目前在免认证规则模板下配置完免认证规则即可生效，无需在认证模板下绑定免认证规则模板。

操作步骤

步骤1 配置免认证规则模板。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**free-rule-template name free-rule-template-name**，创建免认证规则模板，并进入免认证规则模板视图。
缺省情况下，系统自带一个名称为default_free_rule的免认证规则模板。

 说明

当前设备仅支持1个免认证规则模板，即系统自带模板default_free_rule。

3. 执行命令**free-rule rule-id { destination { any | ip { ip-address mask { mask-length | ip-mask } | any } } | source { any | ip { ip-address mask { mask-length | ip-mask } | any } } } ***或**free-rule acl acl-id**，配置免认证规则。
缺省情况下，未配置NAC认证用户的免认证规则。

4. 执行命令**quit**，返回到系统视图。

步骤2 认证模板下绑定免认证规则模板。

1. 执行命令**authentication-profile name authentication-profile-name**，进入认证模板视图。
2. 执行命令**free-rule-template free-rule-template-name**，配置认证模板下绑定的免认证规则模板。

缺省情况下，认证模板下没有绑定任何免认证规则模板。

----结束

3.5.3.5 （可选）配置对用户进行重认证

背景信息

用户在预连接阶段或认证失败阶段，设备会记录用户表项信息，并能够为用户分配受限的网络访问权限（请参见[3.5.3.3 （可选）配置认证事件授权信息](#)）。为使用户能够及时认证成功，获取正常的网络访问权限，设备根据用户表项对没有认证成功的用户进行重认证。

在用户表项老化时间到达之前，如果用户重认证没有成功，设备将删除对应的表项信息，并收回授予用户的网络访问权限；如果用户重认证成功，设备将用户加入到认证成功用户表项，并授予认证成功后的网络访问权限。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**authentication-profile name authentication-profile-name**，进入认证模板视图。

步骤3 执行命令**authentication timer re-authen { pre-authen re-authen-time [wlan-user] | authen-fail re-authen-time [wlan-user] }**，配置预连接用户或认证失败用户进行重认证的周期。

缺省情况下，对于有线用户，对预连接用户或认证失败用户进行重认证的周期为60秒；对于无线用户，对认证失败用户进行重认证的周期为0秒，即关闭认证失败用户的重认证功能。

说明

获取**authen-fail**授权的用户或预连接用户，会加入到认证失败或预连接用户表项。设备默认对表项内的用户进行重认证，重认证周期可以通过以上步骤调节。

当用户数较多时，为减少对设备性能的影响，用户进行重认证的周期可能大于配置的重认证的周期。

步骤4 执行命令**authentication event authen-server-up action re-authen**，使能当认证服务器状态由Down或强制Up转变为真正Up时，设备对处于逃生状态的用户进行重认证。

缺省情况下，当认证服务器状态由Down或强制Up转变为真正Up时，设备不会对处于逃生状态的用户进行重新认证。

说明

设备将RADIUS服务器的状态设置为Down，执行命令**radius-server dead-time dead-time**配置RADIUS服务器恢复激活状态的时间，当**dead-time**超时后，设备会将服务器的状态设置为Up，此状态为强制Up。服务器可以成功收发报文时为真正Up状态。服务器状态从Down或强制Up状态转变为真正Up状态时，设备会对用户进行重认证。

----结束

3.5.3.6 检查认证模板配置结果

背景信息

完成认证模板的配置后，执行以下命令查看配置信息。

操作步骤

- 执行命令**display authentication-profile configuration [name authentication-profile-name]**，查看认证模板的配置信息。
- 执行命令**display free-rule-template configuration [name free-rule-name]**，查看免认证规则模板的配置信息。

----结束

3.5.4 应用 NAC

背景信息

认证模板用来统一管理NAC的相关配置。通过将认证模板绑定到接口视图或VAP模板视图视图下来使能NAC，实现对接口视图或VAP模板视图下的用户进行接入控制。接口视图或VAP模板视图下用户的认证类型由认证模板下绑定的接入模板决定。接入模板的配置请参见[3.5.2 配置接入模板](#)。

使能NAC功能时，需要注意以下几点：

- 支持NAC功能的接口或模板有：二层物理接口、三层物理接口、路由主接口、VLANIF接口、WAN侧接口、端口组、VAP模板。不同接口上认证类型的支持情况如下：
 - 二层物理接口：802.1X认证、MAC认证、二层Portal认证。
 - 三层物理接口和路由主接口：三层Portal认证。

说明

在无线场景下，设备不支持三层Portal认证。

- VLANIF接口：二层Portal认证、三层Portal认证、FAT AP无线场景下MAC帐号优先的Portal认证。
 - WAN侧接口：三层Portal认证。
- 物理接口上不支持包含Portal认证的混合认证方式。
- 对于无线用户通过AP接入，在为用户部署NAC认证时，务必保证AP设备也能够通过认证（可采用将AP设备加入静态用户等方式实现），否则无线用户也无法通过认证。
- 不能在二层以太网接口和其所属VLAN对应的VLANIF接口上同时使能NAC认证功能，否则会导致用户上线后无网络访问权限。另外，无线场景下，不能在VAP模板和VLANIF接口上同时使能NAC认证功能。
- 接口使能NAC功能之后，不能再执行以下命令，反之亦然：

命令	功能
mac-limit	配置接口的最大MAC地址学习个数。
mac-address learning disable	关闭接口的MAC地址学习功能。

命令	功能
port-security enable	配置接口安全功能。

前置任务

配置认证模板，详细配置步骤请参见[3.5.3 配置认证模板](#)。

操作步骤

- 接口下使能NAC。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**interface interface-type interface-number**，进入接口视图。
 - c. 执行命令**authentication-profile authentication-profile-name**，接口下应用认证模板。
缺省情况下，接口下没有应用认证模板。
- VAP模板下使能NAC。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**wlan**，进入WLAN视图。
 - c. 执行命令**wlan ac**，进入WLAN视图。
 - d. 执行命令**vap-profile name profile-name**，进入VAP模板视图。
 - e. 执行命令**authentication-profile authentication-profile-name**，VAP模板下应用认证模板。
缺省情况下，VAP模板下没有应用认证模板。

----结束

检查配置结果

执行命令**display authentication interface interface-type interface-number**，查看接口下NAC认证方式的配置信息。

3.5.5（可选）配置 NAC 扩展功能

3.5.5.1 配置 802.1X 认证相关的扩展功能

3.5.5.1.1 配置发送 802.1X 认证请求报文的时间间隔

背景信息

802.1X认证请求报文的时间间隔包括两种：

- 在客户端主动发起认证的情况下，当设备向客户端发送单播Request/Identity请求报文后，将同时启动tx-period定时器。若在该定时器规定的时长内，设备没有收到客户端的响应，则将重发认证请求报文。

- 为了对不支持主动发起认证的802.1X客户端进行认证，设备会在启动802.1X功能的端口定期地发送组播Request/Identity报文，发送的间隔是tx-period定时器的值。

若设备重传请求报文的次数达到配置的最大值（通过命令**dot1x retry max-retry-value**）后，仍然没有得到客户端响应，则停止发送认证请求。

通常情况下，客户端认证失败时，为使得客户端能够继续访问网络，会在设备上启用备用机制（Portal认证或授权特定访问权限）。未配置MAC旁路认证时，EAP-Request/Identity请求超时计算公式如下所示：

$$\text{Timeout} = (\text{max-retry-value} + 1) * \text{tx-period-value}$$

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dot1x timer tx-period tx-period-value**，配置发送802.1X认证请求报文的时间间隔。

缺省情况下，发送802.1X认证请求的时间间隔为30秒。

----结束

3.5.5.1.2 配置 802.1X 快速部署功能

背景信息

用户使用非系统自带的802.1X客户端软件，即使用第三方802.1X客户端软件时，才会配置802.1X快速部署功能。

在802.1X网络部署中，若需为每一个接入用户下载、升级802.1X客户端软件，在用户数目较多时会给管理员带来巨大的工作量。通过为用户配置免认证网络访问权限以及URL重定向功能，可以实现用户802.1X客户端的快速部署。

在802.1X认证成功前，通过为用户授予免认证网络访问权限，用户就能够访问免认证网络内的资源。通过配置802.1X用户URL重定向功能，并且提供重定向URL的服务器同时位于用户的免认证网络资源内，那么当用户访问网络时，设备会将用户访问的URL重定向到已配置的URL（例如，重定向到802.1X客户端下载界面），这样就能够实现802.1X客户端的快速部署。

前提条件

已通过[3.5.3.3（可选）配置认证事件授权信息](#)或[3.5.3.4（可选）配置用户的免认证授权信息](#)将提供重定向URL的服务器配置为免认证资源。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dot1x url url-string**，配置802.1X认证的URL重定向功能。

缺省情况下，未配置802.1X认证的重定向URL。

----结束

3.5.5.1.3 配置设备允许记录的异常 802.1X 认证的 EAP 报文数

背景信息

802.1X认证失败时，为了定位故障原因，需要查看EAP报文交互信息。通过配置该功能，指定设备允许记录的异常802.1X认证的EAP报文数，设备会记录异常802.1X认证的EAP报文信息。方便故障定位。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dot1x abnormal-track cache-record-num *cache-record-num***，配置设备允许记录的异常802.1X认证的EAP报文数。

缺省情况下，配置设备允许记录的异常802.1X认证的EAP报文数为20。

----结束

3.5.5.1.4 配置 HTTPS 重定向功能

背景信息

802.1X认证场景中，对于HTTPS报文部署WEB页面推送功能时，需要使能HTTPS重定向功能，否则WEB页面推送功能不生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**authentication https-redirect enable**，使能802.1X认证HTTPS重定向功能。

缺省情况下，802.1X认证HTTPS重定向功能处于未使能状态。

----结束

3.5.5.2 配置 Portal 认证相关的扩展功能

3.5.5.2.1 配置 iOS 系统的 CNA 旁路功能

背景信息

iOS系统提供了CNA（Captive Network Assistant）功能，该功能会使iOS设备（iPhone、iPad、iMac）在关联到WLAN后能够自动探测网络是否畅通，如果网络不通，iOS设备会自动弹出输入用户名和密码的界面。此时，如果用户取消输入用户名和密码，iOS设备将会自动断开WLAN关联状态。

在使能Portal认证后，针对iOS设备，由于CNA功能的存在，会导致用户关联到WLAN后必须立刻输入用户名和密码，否则设备自动断开WLAN关联状态，这导致无法满足为认证前用户提供特定的网络资源等需求。对于这种情况，可使能iOS系统的CNA旁路功能，之后就能够实现在Portal认证成功之前，WLAN关联状态不会自动断开，用户在认证前可以访问特定的免认证资源。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**portal captive-bypass enable**，使能iOS系统的CNA旁路功能。

缺省情况下，未使能iOS系统的CNA旁路功能。

----结束

3.5.5.2.2 配置 iOS 系统的 CNA 自适应功能

背景信息

当用户使用iOS终端设备（iPhone、iPad、iMac）接入WLAN时，iOS设备自身的CNA（Captive Network Assistant）工具固定对http://captive.apple.com进行探测，如果网络畅通，那么iOS设备会收到内容为Success的回应；反之，iOS设备调用浏览器再次进行探测，实现自动弹出页面的功能。具体流程如下：

1. 终端关联到SSID后，终端发送一个HTTP 1.0请求到http://captive.apple.com，报文中的User-Agent是CaptiveNetworkSupport wispr。
2. 如果收到的不是期望的Success页面，即http://www.apple.com/library/test/success.html，那么终端认为连接网络失败，就会调用浏览器再次发出HTTP 1.1请求到http://captive.apple.com，报文中的User-Agent是Mozilla/5.0 (iPhone; CPU iPhone OS 9_3_3 like Mac OS X) AppleWebKit/601.1.46 (KHTML, like Gecko) Mobile/13G34（不同iOS终端或版本之间稍有差异）。
3. 此时，终端自动弹出了Portal的认证页面，用户输入账号密码后即可连接无线网络。

但是，iOS终端设备CNA探测失败可能导致iOS终端的WiFi信号无法点亮。因此，需要通过以下方法解决：

- 方法一：在设备系统视图下执行命令**portal captive-bypass enable**对所有CaptiveNetworkSupport wispr（UA）探测构造Success回应，让iOS终端误认为网络已连通，从而点亮信号。该配置的缺点是iOS终端无法自动弹出页面，需要手动打开浏览器访问网站才可以重定向出认证页面。
- 方法二：在设备系统视图下执行命令**portal captive-adaptive enable**，对第一次CaptiveNetworkSupport wispr（UA）探测重定向，后续的CaptiveNetworkSupport wispr（UA）探测回应Success（200 OK），使得iOS终端可以自动弹出页面，并点亮WiFi信号。

说明

用户访问的免认证资源不能包含captive.apple.com网址，否则终端无法自动弹出Portal认证页面。

如果Portal认证页面为HTTPS类型，只有当HTTPS网址为域名网址，并且域名证书合法时，终端才能自动弹出Portal认证页面。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**portal captive-adaptive enable**，使能iOS系统的CNA自适应功能。

缺省情况下，未使能iOS系统的CNA自适应功能。

同时执行命令**portal captive-adaptive enable**和**portal captive-bypass enable**时，两者中后配置的命令生效。

----结束

3.5.5.2.3 配置允许接入的 Portal 认证用户数

背景信息

当管理员需要对设备允许接入的最大Portal认证用户数进行限制的时候，可以进行以下配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**portal max-user user-number**，配置允许接入的Portal认证用户数。

缺省情况下，在规格范围内，设备允许接入的Portal认证用户数没有限制。

步骤3 （可选）执行命令**portal user-alarm percentage percent-lower-value percent-upper-value**，配置Portal认证用户数的告警阈值百分比。

缺省情况下，Portal认证用户数的下限告警阈值百分数为50，上限告警阈值百分数为100。

当实际上线的Portal认证用户数占配置的最大用户数比例高于上限告警阈值百分比时，设备将会发出告警。之后，如果该比例下降到等于或小于下限告警阈值百分比时，设备会发出恢复告警。

----结束

3.5.5.2.4 （可选）配置 3G/LTE 链路断开连接后，强制 Portal 认证用户下线

背景信息

当路由器作为移动互联网关部署在公交车、地铁时，用户在通过Portal认证后，才可以接入车载Wi-Fi网络并通过3G/LTE接口访问外网。当3G/LTE链路断开连接后，用户并不会立即下线，却会立即发现自己不能访问任何网络页面，从而造成用户体验下降。

在3G/LTE接口上配置Portal认证用户强制下线后，在3G/LTE链路断开连接后，设备将Portal认证用户强制下线，而强制下线的用户可以继续访问路由器的内部网络资源，从而提升用户体验。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface cellular interface-number**，进入Cellular接口视图。

步骤3 执行命令**cut web-authentication-user [domain domain-name | ssid ssid]**，配置在3G/LTE链路断开连接后，设备将Portal认证用户强制下线。

缺省情况下，在3G/LTE链路断开连接后，Portal认证用户仍然在线。

----结束

3.5.5.3 配置用户静默功能

背景信息

在NAC认证过程中，若用户在短时间内频繁认证失败，一方面会对系统造成冲击，另一方面存在攻击者通过多次尝试输入用户名和密码的方式暴力破解用户名和密码的风险。

使能静默功能后，若某一用户在60秒内认证失败的次数超过规定的值，则设备会将该用户静默一段时间，在静默时间内，设备会丢弃该用户的NAC认证请求，从而避免用户在短时间内频繁认证失败。

说明

静默表满规格时不允许非静默表中的新用户接入。

操作步骤

- 配置802.1X用户的静默功能。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**dot1x quiet-period**，使能802.1X用户的静默功能。
缺省情况下，已使能802.1X用户的静默功能。
 - c. （可选）执行命令**dot1x quiet-times fail-times**，配置802.1X用户被静默前60秒内允许认证失败的次数。
缺省情况下，802.1X用户被静默前60秒内允许认证失败的次数为10次。
 - d. （可选）执行命令**dot1x timer quiet-period quiet-period-value**，配置认证失败的802.1X用户被静默的时间。
缺省情况下，认证失败的802.1X用户被静默的时间为60秒。
- 配置MAC用户的静默功能。

说明

必须通过命令**undo authentication event action authorize**关闭用户在认证成功前各阶段的网络访问权限后，MAC用户的静默功能才能生效。但是，在MAC用户混合认证场景中，MAC用户的静默功能不生效。

- a. 执行命令**system-view**，进入系统视图。
- b. （可选）执行命令**mac-authen quiet-times fail-times**，配置MAC用户被静默前60秒内允许认证失败的次数。
缺省情况下，MAC用户被静默前60秒内允许认证失败的次数为10次。
- c. 执行命令**mac-authen timer quiet-period quiet-period-value**，配置认证失败的MAC用户被静默的时间。
缺省情况下，认证失败的MAC用户被静默的时间为60秒。*quiet-period-value*取值为0时，表示关闭MAC用户的静默功能。
- 配置Portal认证用户的静默功能。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**portal quiet-period**，使能Portal认证静默功能。
缺省情况下，已使能Portal认证用户的静默功能。
 - c. （可选）执行命令**portal quiet-times fail-times**，配置Portal认证用户被静默前60秒内允许认证失败的次数。

缺省情况下，Portal认证用户被静默前60秒内允许认证失败的次数为10次。

- d. （可选）执行命令**portal timer quiet-period quiet-period-value**，配置认证失败的Portal认证用户被静默的时间。

缺省情况下，认证失败的Portal认证用户被静默的时间为60秒。

----结束

3.5.5.4 配置 WEB 页面推送功能

背景信息

在用户认证通过后，通过配置WEB页面推送功能，可以实现设备在接收到用户首次进行WEB访问发出的HTTP/HTTPS报文时，强制用户访问指定网页。这种功能除了能够为用户提供广告推送等服务，还可以通过用户发送的HTTP/HTTPS报文获取到用户的终端信息，以便为其他功能服务。有两种方式可以推送WEB页面：

1. URL方式：根据WEB页面的URL直接进行推送。
2. URL模板方式：根据URL模板进行推送。该方式需先创建URL模板，然后在URL模板中配置需要推送的WEB页面的URL以及URL中的各参数。

对于HTTPS/HTTP报文，强推功能必须和重定向ACL配合使用才能生效，如果用户表中一直存在重定向ACL，则只要用户发出的HTTPS/HTTP报文匹配重定向ACL规则，就会进行强推。可以执行命令**redirect-acl**配置重定向ACL。

管理员希望对Portal认证成功的用户，在匹配重定向ACL时，通过重定向URL在指定的WEB页面再做一次Portal认证。不配置命令**authentication redirect-acl original-url enable**，在强制用户进行Portal认证后，认证服务器无法从重定向URL携带参数中获取原始URL地址，客户无法从认证页面跳转至认证前页面。配置该命令**authentication redirect-acl original-url enable**，认证服务器可以通过原始URL地址属性跳转至用户认证前页面。

说明

内置Portal认证不支持WEB页面推送功能。

AR下接FIT AP场景，该功能对从FIT AP上线的用户不生效。

WEB页面推送功能只有在认证通过后收到的第一个HTTP/HTTPS报文时才会推送，后续收到HTTP/HTTPS报文将不会推送。在实际应用中，终端连接上网后，浏览器尚未发出HTTP/HTTPS报文前，应用程序或APP就会发出HTTP/HTTPS报文，把唯一的一次推送机会使用掉，因此该功能在实际使用中基本不可用。

操作步骤

- URL方式
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**aaa**，进入AAA视图。
 - c. 执行命令**domain domain-name**，创建并进入AAA域视图。

缺省情况下，设备存在两个域：“default”和“default_admin”。“default”用于普通接入用户的域，“default_admin”用于管理员的域。
 - d. 执行命令**force-push url url-address**，使能强制推送URL功能。

缺省情况下，未使能强制推送URL功能。
- URL模板方式

- a. 创建并配置URL模板。
 - i. 执行命令**system-view**，进入系统视图。
 - ii. 执行命令**url-template name template-name**，创建URL模板并进入URL模板视图。
缺省情况下，设备上未创建URL模板。
 - iii. 执行命令**url [push-only] url-string [ssid ssid]**，配置强制推送的URL。
缺省情况下，未配置强制推送的URL。
用户接入的SSID需与设备配置的SSID一致，否则无法给用户推送URL。
 - iv. 执行命令**url-parameter { device-ip device-ip-value | device-mac device-mac-value | ap-ip ap-ip-value | ap-mac ap-mac-value | login-url url-key url | redirect-url redirect-url-value | ssid ssid-value | sysname sysname-value | user-ipaddress user-ipaddress-value | user-mac user-mac-value | user-vlan user-vlan-value | esn esn-value } ***，配置URL中携带的参数。
缺省情况下，URL中未携带参数。
 - v. 执行命令**url-parameter mac-address format delimiter delimiter { normal | compact }**，配置URL参数中MAC地址的格式。
缺省情况下，URL参数中MAC地址的格式为XXXXXXXXXXXX。
 - vi. 执行命令**parameter { start-mark parameter-value | assignment-mark parameter-value | isolate-mark parameter-value } ***，配置URL中的符号。
缺省情况下，URL中指定URL参数开始的符号为“?”，赋值符号为“=”，不同参数之间的分隔符为“&”。
 - vii. 执行命令**quit**，返回到系统视图。
- b. 执行命令**aaa**，进入AAA视图。
- c. 执行命令**domain domain-name**，创建并进入AAA域视图。
缺省情况下，设备存在两个域：“default”和“default_admin”。“default”用于普通接入用户的域，“default_admin”用于管理员的域。
- d. 执行命令**force-push url-template template-name**，使能强制推送URL模板功能。
缺省情况下，未使能强制推送URL模板功能。

----结束

3.5.5.5 （可选）配置 HTTP 协议认证计费功能

背景信息

传统的NAC场景通常采用Portal协议和RADIUS协议进行认证，这些认证方式常用于运营商及需要提供完整解决方案的企业中。在互联网场景中，设备常需要与互联网或云服务器进行对接，所以现在提供基于HTTP协议的认证方式。用户通过认证计费服务器认证访问外网并获得用户的授权信息包括允许用户上线的时间、流量、用户带宽等。用户访问外网后，设备将定时向认证计费服务器发送计费报文，服务器将根据用户登录外网时使用的流量进行计费。当用户上线的时间和流量超过授权时长和授权流量时，设备将强制用户下线，并发送用户下线信息给认证计费服务器。

说明

仅AR303W支持此功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface wlan-bss wlan-bss-number**，创建并进入WLAN-BSS接口视图。

步骤3 执行命令**web-service access enable**，使能WLAN-BSS接口的认证计费功能。

缺省情况下，WLAN-BSS接口的认证计费功能处于未使能状态。

步骤4 执行命令**quit**，返回到系统视图。

步骤5 执行命令**web-service aaa server url authorize-enable**，配置认证计费服务器的URL地址并使能用户授权信息的接收功能。用户授权信息包括允许用户上线的时间、流量、用户带宽等。

缺省情况下，未配置认证计费服务器的URL地址，用户授权信息的接收功能处于未使能状态。

步骤6 （可选）执行命令**web-service accounting enable**，使能设备向认证计费服务器发送计费报文功能。

缺省情况下，设备向认证计费服务器发送计费报文功能处于未使能状态。

当需要对用户访问外网的流量进行计费时，可以选择配置该命令。

步骤7 （可选）执行命令**web-service accounting interval interval**，配置设备向认证计费服务器发送计费报文的时间间隔。

缺省情况下，设备向认证计费服务器发送计费报文的时间间隔为30秒。

当需要设备定时向认证计费服务器发送计费报文时，可以选择配置该命令。

说明

在执行此命令前需要先执行命令**web-service accounting enable**，使能设备向认证计费服务器发送计费报文功能。

----结束

3.5.5.6 配置允许用户连续认证失败的最大次数

背景信息

当管理员需要对设备允许用户连续认证失败的最大次数进行调整的时候，可以进行以下配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**authentication authen-fail fail-times fail-times**，配置允许用户连续认证失败的最大次数。

缺省情况下，允许用户连续认证失败的最大次数为1。

----结束

3.5.5.7 调整 ACL 规则的匹配顺序

背景信息

针对于NAC用户，缺省情况下，ACL规则的匹配顺序为rule id越大匹配优先级越高。如果用户希望ACL规则的匹配顺序为rule id越小匹配优先级越高，则可以调整ACL规则的匹配顺序。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**access-user acl-privilege-revert**，配置ACL规则的匹配顺序为rule id越小匹配优先级越高。

缺省情况下，ACL规则的匹配顺序为rule id越大匹配优先级越高。

该命令配置完成会提示需要重启，设备重启后才会生效。

----结束

3.5.5.8 配置用户隔离功能

背景信息

如果希望组间或组内的用户相互间不能访问，则可以配置用户隔离功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**user-group group-name**，创建用户组并进入用户组视图。

步骤3 执行命令**user-isolated { inter-group | inner-group } ***，配置用户组视图下的组间、组内隔离。

缺省情况下，用户组视图下没有组间、组内隔离。

用户认证成功上线后，通过RADIUS服务器动态授权下发用户组，则已配置的用户组视图下的组间、组内隔离不能被修改和删除。

----结束

3.5.5.9 配置用户下线探测报文源地址

背景信息

为确保用户在线状态正常，设备会向在线用户发送ARP下线探测报文，如果用户在下线探测周期内没有回应，则设备认为该用户已下线。

说明

- 该功能仅对有线用户生效。
- 该功能对三层Portal认证用户不生效。
- 正常情况下，设备发送默认源IP地址的ARP探测报文后，实际在线的客户端会立即回应ARP应答报文。如果客户端实际在线，但不回应设备的ARP探测报文，设备就会将客户端下线，为解决该问题，可以使用以下两种方式：
 - 通过命令**access-user arp-detect vlan *vlan-id* ip-address *ip-address* mac-address *mac-address***，指定ARP探测报文的VLAN ID、源IP地址和源MAC地址。
 - 如果不希望使用以上方式，也可以通过命令**authentication timer handshake-period *handshake-period***，适当调大探测周期。这是因为，对于不会立即回应设备发送的ARP探测报文的客户端，设备支持识别客户端发送的免费ARP报文，但是免费ARP报文发送的周期不固定，调大探测周期有利于探测到该报文。
- 在配置用户下线探测报文的源IP地址或源MAC地址时，命令配置优先级由高到低依次为：命令**access-user arp-detect vlan *vlan-id* ip-address *ip-address* mac-address *mac-address***、命令**access-user arp-detect fallback *ip-address* { *mask* | *mask-length* }**、命令**access-user arp-detect default ip-address *ip-address***。同时配置时，优先级高的命令生效。
- 对于物理接口下的在线用户，用户必须重新上线或者设备对其进行重认证之后本命令功能才会生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置用户下线探测报文的源地址。

- 执行命令**access-user arp-detect default ip-address *ip-address***，配置用户下线探测报文的默认源IP地址。
缺省情况下，用户下线探测报文的默认源IP地址是0.0.0.0。
- 执行命令**access-user arp-detect vlan *vlan-id* ip-address *ip-address* mac-address *mac-address***，配置指定VLAN内用户下线探测报文的源IP地址和源MAC地址。
缺省情况下，未配置指定VLAN内用户下线探测报文的源IP地址和源MAC地址。
建议用户下线探测报文的源IP地址和源MAC地址配置为用户网关的IP地址和MAC地址。
- 执行命令**access-user arp-detect fallback *ip-address* { *mask* | *mask-length* }**，配置计算下线探测报文源地址所需的IP地址。
缺省情况下，未配置计算下线探测报文源地址所需的IP地址。

说明

用户下线探测报文使用的源IP地址优先级：

1. 用户所在VLAN对应VLANIF接口下的IP地址和MAC地址，且与用户同网段
2. 命令**access-user arp-detect vlan *vlan-id* ip-address *ip-address* mac-address *mac-address***指定的VLAN内用户下线探测报文的源IP地址
3. 基于**access-user arp-detect fallback *ip-address* { *mask* | *mask-length* }**计算出的下线探测报文源地址
4. 命令**access-user arp-detect default ip-address *ip-address***指定的用户下线探测报文的默认源IP地址

步骤3 执行命令**access-user arp-detect delay *delay***，配置下线探测报文延迟发送时间。

缺省情况下，下线探测报文延迟发送时间为10秒。

----结束

3.5.5.10 使能动态调整 NAC 用户报文处理速率功能

背景信息

当设备CPU或内存占用率很高时（譬如CPU或内存占有率大于80%），此时如果仍有大量NAC用户进行接入认证或者下线，这会给设备CPU带来很大的负担。使能设备对NAC用户报文处理速率动态调整功能后，当设备的CPU或内存占用率过高时，设备将动态调整每秒能够处理的NAC用户报文数，这在一定程度上能够减轻设备CPU的负担。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**authentication speed-limit auto**，使能动态调整NAC用户报文处理速率功能。

----结束

3.5.5.11 配置 URL 编解码功能

背景信息

为满足WEB应用安全，如果输出到客户端的数据来自不可信的数据源时，需要对该数据进行编码，WEB应用中常见的编码方式包含URL编码。打开URL编解码功能后，重定向URL中一些特殊字符被转换成安全的形式，使得客户端不会将其当作语法符号或指令，以防止原本预期的语义被更改，避免跨站脚本攻击与各种类型的注入攻击。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**portal url-encode enable**，打开URL编解码功能。

缺省情况下，打开URL编解码功能。

----结束

检查配置结果

执行命令**display portal url-encode configuration**，查看URL编解码功能的配置信息。

3.5.5.12 配置 NAC 认证用户数的告警阈值

背景信息

配置NAC认证用户数的告警阈值。当NAC认证用户达到设备规格的一定比例时，设备会发出告警。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**authentication user-alarm percentage percent-lower-value percent-upper-value**，配置NAC认证用户数的告警阈值百分比。

缺省情况下，NAC认证用户数的下限告警阈值百分数为50，上限告警阈值百分数为100。

----结束

检查配置结果

执行命令**display authentication user-alarm configuration**，查看NAC认证用户数的告警阈值百分比。

3.5.5.13 配置 AP 为免认证用户

背景信息

当AC上二层物理接口Port1连接的局域网中既有有线用户又有AP时，如果在该接口已开启802.1X认证、MAC认证实现基于接口的网络接入控制时，设备会将AP视为一个有线用户，从而使得AP也必须先通过认证才能获得接入授权，而AP不支持通过802.1X认证、MAC认证方式接入AC，导致AP不能与AC建立连接。

为了解决此问题，管理员可以将AP配置为免认证用户，即在设备上已使能802.1X认证、MAC认证的情况下，AP不需要进行认证，解决AP与AC不能建立连接的问题。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface interface-type interface-number**，进入指定的接口视图。

步骤3 执行命令**authentication static-user mac-address vlan-id**，配置AP为免认证静态用户。

缺省情况下，没有配置AP为免认证用户。

其中，*mac-address*表示指定AP的MAC地址，*vlan-id*表示该AP的管理VLAN。

说明

该命令仅支持在二层以太网接口下配置。

----结束

3.5.5.14 检查 NAC 扩展功能配置结果

背景信息

完成扩展功能的配置后，执行以下命令查看配置信息。

操作步骤

- 执行命令**display portal quiet-user { all | user-ip *ip-address* | server-ip *ip-address* }**，查看Portal认证静默用户信息。
- 执行命令**display mac-authen quiet-user { all | mac-address *mac-address* }**，查看MAC认证静默用户信息。
- 执行命令**display dot1x quiet-user { all | mac-address *mac-address* }**，查看802.1X认证静默用户信息。

----结束

3.6 维护 NAC

3.6.1 配置 NAC 告警上报功能

背景信息

为了方便运维，及时了解NAC网络的运行状态，可以配置NAC告警上报功能，将NAC运行的状态变化况通知给网管系统，提醒用户注意。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**snmp-agent trap enable feature-name mid_eapol [trap-name { hwmacauthenmaxuseralarm | hwsrvcfgeapmaxuseralarm }]**，打开DOT1X模块的告警开关。

缺省情况下，DOT1X模块的告警开关处于打开状态。

步骤3 执行命令**snmp-agent trap enable feature-name mid_web [trap-name { hwportalmaxuseralarm | hwportaluserclearalarm | hwportalserverdown | hwportalserverup }]**，打开WEB认证模块的告警开关。

缺省情况下，WEB认证模块的告警开关处于打开状态。

----结束

检查配置结果

- 执行命令**display snmp-agent trap feature-name mid_eapol all**，查看DOT1X模块的所有告警开关的信息。
- 执行命令**display snmp-agent trap feature-name mid_web all**，查看WEB认证模块的所有告警开关的信息。

3.6.2 清除 NAC 认证统计信息

背景信息

须知

清除统计信息后，以前的统计信息将无法恢复，请慎重操作。

操作步骤

- 在用户视图下执行命令**reset dot1x statistics**清除802.1X的统计信息。
- 在用户视图下执行命令**reset mac-authen statistics**清除MAC地址认证的统计信息。

----结束

3.6.3 监控 NAC 认证运行状况

背景信息

在日常维护工作中，可以在任意视图下执行以下命令，了解NAC的运行情况。

操作步骤

- 执行命令**display access-user**，查看NAC接入用户信息。
- 执行命令**display dot1x**，查看802.1X认证的相关信息。
- 执行命令**display mac-authen**，查看MAC认证相关信息。
- 执行命令**display portal**，查看Portal认证相关信息。
- 执行命令**display portal local-server connect**，查看内置Portal服务器上Portal认证用户的连接状态。
- 执行命令**display portal-server state**或**display server-detect state**，查看Portal服务器状态信息。
- 执行命令**display mac-address authen**，查看系统当前存在的authen类型的MAC地址表项。
- 执行命令**display mac-address pre-authen**，查看系统当前存在的Pre-authen类型的MAC地址表项。
- 执行命令**display user-group [group-name]**，查看用户组的配置信息。
- 执行命令**display access-user-num [interface wlan-dbss wlan-dbss-interface-id]**，查看VAP内在线用户数。

----结束

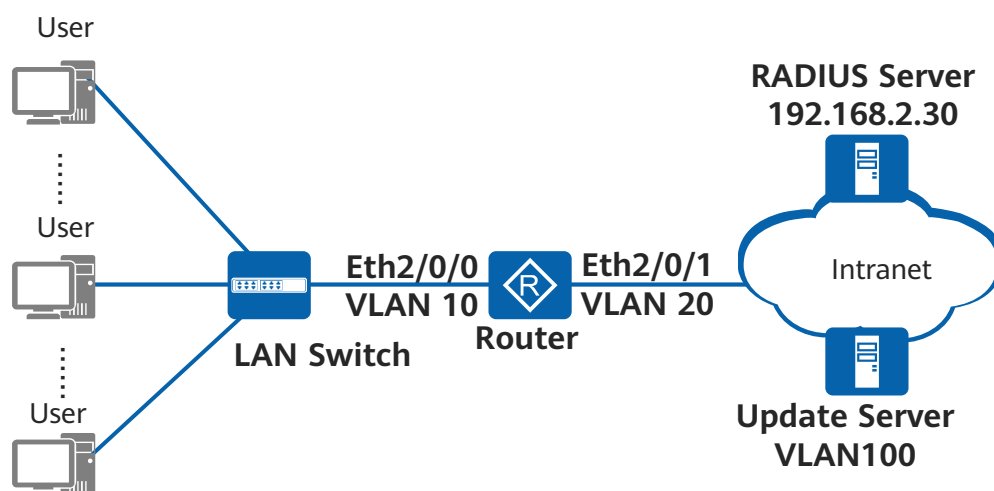
3.7 NAC 配置举例

3.7.1 配置 802.1X 认证示例

组网需求

如图3-41所示，某公司内部大量用户终端通过Router（作为接入设备）的接口Eth2/0/0接入网络。在该网络运行一段时间后，发现存在用户对公司内网进行攻击。为确保网络的安全性，管理员需对用户终端的网络访问权限进行控制，只有用户终端通过认证后，Router才允许其访问Internet中的资源。

图 3-41 配置 802.1X 认证组网图



配置思路

为实现对用户网络访问权限进行限制的需求，在将IP地址为192.168.2.30的服务器用作RADIUS服务器后，管理员可在Router上配置802.1X认证功能。

具体配置思路如下（均在Router上进行配置）：

1. 创建并配置RADIUS服务器模板、AAA方案以及认证域，并在ISP域下绑定RADIUS服务器模板与AAA方案。保证了Router与RADIUS服务器之间的信息交互。
2. 配置802.1X认证，实现对办公区内员工的网络访问权限进行严格控制。具体配置包括：
 - a. 配置802.1X接入模板
 - b. 配置认证模板
 - c. 接口下使能802.1X认证

说明

配置本举例之前，需确保网络中各设备之间已能互通。

本举例只包括Router上的配置，LAN Switch和RADIUS服务器的配置这里不做相关说明。

操作步骤

步骤1 创建VLAN并配置接口允许通过的VLAN，保证网络通畅

创建VLAN10和VLAN20。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20
```

配置Router与用户连接的接口Eth2/0/0为Access类型接口，并将Eth2/0/0加入VLAN10。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type access
[Router-Ethernet2/0/0] port default vlan 10
[Router-Ethernet2/0/0] quit
```

说明

设备与用户连接的接口类型与接口加入的VLAN应以用户实际所属VLAN为准，此处假设所有的用户都被划分到VLAN10。

配置Router连接RADIUS服务器的接口Eth2/0/1为Access类型接口，并将Eth2/0/1加入VLAN20。

```
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type access
[Router-Ethernet2/0/1] port default vlan 20
[Router-Ethernet2/0/1] quit
```

步骤2 创建并配置RADIUS服务器模板、AAA认证方案以及认证域

创建并配置RADIUS服务器模板“rd1”。

```
[Router] radius-server template rd1
[Router-radius-rd1] radius-server authentication 192.168.2.30 1812
[Router-radius-rd1] radius-server shared-key cipher YsHsjx_202206
[Router-radius-rd1] quit
```

创建AAA方案“abc”并配置认证方式为RADIUS。

```
[Router] aaa
[Router-aaa] authentication-scheme abc
[Router-aaa-authen-abc] authentication-mode radius
[Router-aaa-authen-abc] quit
```

创建认证域“isp1”，并在其上绑定AAA认证方案“abc”与RADIUS服务器模板“rd1”。

```
[Router-aaa] domain isp1
[Router-aaa-domain-isp1] authentication-scheme abc
[Router-aaa-domain-isp1] radius-server rd1
[Router-aaa-domain-isp1] quit
[Router-aaa] quit
```

测试用户是否能够通过RADIUS模板的认证。（已在RADIUS服务器上配置了测试用户test@huawei.com，用户密码YsHsjx_202206）

```
[Router] test-aaa test@huawei.com YsHsjx_202206 radius-template rd1
Info: Account test succeeded.
```

步骤3 配置802.1X认证

配置802.1X接入模板“d1”。

说明

802.1X接入模板默认采用EAP认证方式。请确保RADIUS服务器支持EAP协议，否则无法处理802.1X认证请求。

```
[Router] dot1x-access-profile name d1
[Router-dot1x-access-profile-d1] quit
```

配置认证模板“p1”，并在其上绑定802.1X接入模板“d1”、指定认证模板下用户的强制认证域为“isp1”。


```
[Router] authentication-profile name p1
[Router-authen-profile-p1] dot1x-access-profile d1
[Router-authen-profile-p1] access-domain isp1 force
[Router-authen-profile-p1] quit
```

在接口Eth2/0/0上绑定认证模板“p1”，使能802.1X认证。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] authentication-profile p1
[Router-Ethernet2/0/0] quit
```

步骤4 验证配置结果

1. 执行命令**display dot1x**查看802.1X认证的各项配置信息。从显示信息中能够看到接口Eth2/0/0下已使能802.1X认证（**802.1X protocol is Enabled**）。
2. 用户在终端上启动802.1X客户端，输入用户名和密码，开始认证。
3. 如果用户输入的用户名和密码验证正确，客户端页面会显示认证成功信息。用户即可访问网络。
4. 用户上线后，管理员可在设备上执行命令**display access-user**查看在线802.1X用户信息。

----结束

配置文件

Router的配置文件

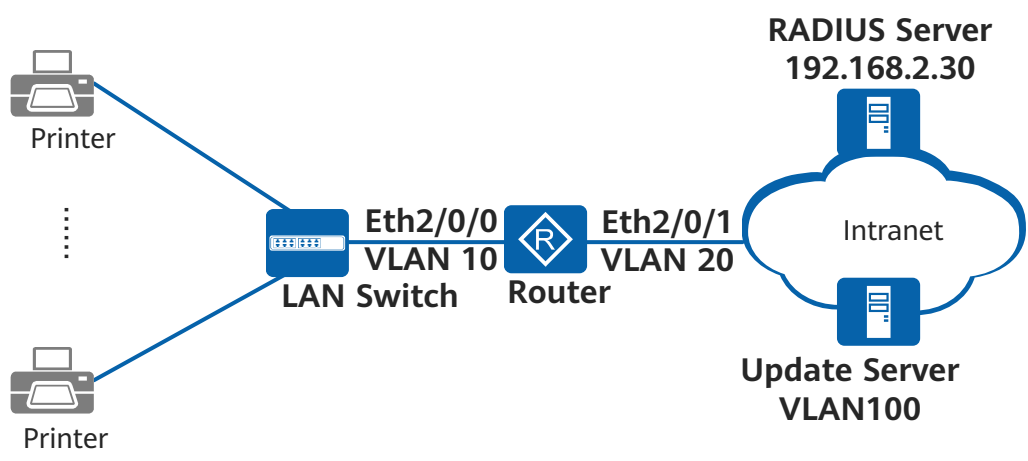
```
#
sysname Router
#
vlan batch 10 20
#
authentication-profile name p1
dot1x-access-profile d1
access-domain isp1 force
#
radius-server template rd1
radius-server shared-key cipher %^%#5Cz2!R*M%NaEr^6.]')L/$!!xTKZ<!!!!!!%^^%#
radius-server authentication 192.168.2.30 1812 weight 80
#
aaa
authentication-scheme abc
authentication-mode radius
domain isp1
authentication-scheme abc
radius-server rd1
#
interface Ethernet2/0/0
port link-type access
port default vlan 10
authentication-profile p1
#
interface Ethernet2/0/1
port link-type access
port default vlan 20
#
dot1x-access-profile name d1
#
return
```

3.7.2 配置 MAC 认证示例

组网需求

如图3-42所示，某公司内部大量打印机通过Router（作为接入设备）的接口Eth2/0/0接入网络。在该网络运行一段时间后，为增强网络的安全性，管理员需对打印机的网络访问权限进行控制。只有打印机通过认证后，Router才允许其访问网络中的资源。

图 3-42 配置 MAC 认证组网图



配置思路

由于打印机无法安装和使用802.1X客户端，为实现对其网络访问权限进行限制的需求，管理员可在Router上配置MAC认证功能。

具体配置思路如下（均在Router上进行配置）：

- 1. 创建并配置RADIUS服务器模板、AAA方案以及认证域，并在ISP域下绑定RADIUS服务器模板与AAA方案。保证了Router与RADIUS服务器之间的信息交互。
- 2. 配置MAC认证，实现对哑终端的网络访问权限进行控制。具体配置包括：
 - a. 配置MAC接入模板
 - b. 配置认证模板
 - c. 接口下使能MAC认证

说明

配置本举例之前，需确保网络中各设备之间已能互通。
本举例只包括Router上的配置，LAN Switch和RADIUS服务器的配置这里不做相关说明。

操作步骤

步骤1 创建VLAN并配置接口允许通过的VLAN，保证网络通畅

创建VLAN10和VLAN20。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20
```

配置Router与用户连接的接口Eth2/0/0为Access类型接口，并将Eth2/0/0加入VLAN10。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type access
[Router-Ethernet2/0/0] port default vlan 10
[Router-Ethernet2/0/0] quit
```

说明

设备与用户连接的接口类型与接口加入的VLAN应以用户实际所属VLAN为准，此处假设所有的用户都被划分到VLAN10。

配置Router连接RADIUS服务器的接口Eth2/0/1为Access类型接口，并将Eth2/0/1加入VLAN20。

```
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type access
[Router-Ethernet2/0/1] port default vlan 20
[Router-Ethernet2/0/1] quit
```

步骤2 创建并配置RADIUS服务器模板、AAA认证方案以及认证域

创建并配置RADIUS服务器模板“rd1”。

```
[Router] radius-server template rd1
[Router-radius-rd1] radius-server authentication 192.168.2.30 1812
[Router-radius-rd1] radius-server shared-key cipher YsHsjx_202206
[Router-radius-rd1] quit
```

创建AAA方案“abc”并配置认证方式为RADIUS。

```
[Router] aaa
[Router-aaa] authentication-scheme abc
[Router-aaa-authen-abc] authentication-mode radius
[Router-aaa-authen-abc] quit
```

创建认证域“isp1”，并在其上绑定AAA认证方案“abc”与RADIUS服务器模板“rd1”。

```
[Router-aaa] domain isp1
[Router-aaa-domain-isp1] authentication-scheme abc
[Router-aaa-domain-isp1] radius-server rd1
[Router-aaa-domain-isp1] quit
[Router-aaa] quit
```

测试用户是否能够通过RADIUS模板的认证。（已在RADIUS服务器上配置了测试用户test@huawei.com，用户密码YsHsjx_202206）

```
[Router] test-aaa test@huawei.com YsHsjx_202206 radius-template rd1
Info: Account test succeeded.
```

步骤3 配置MAC认证

配置MAC接入模板“m1”。

说明

MAC接入模板中，MAC认证用户的用户名和密码默认均为不带分隔符“-”的MAC地址。需要保证RADIUS服务器上配置的MAC用户名和密码格式与接入设备上的保持一致。

```
[Router] mac-access-profile name m1
[Router-mac-access-profile-m1] quit
```

配置认证模板“p1”，并在其上绑定MAC接入模板“m1”、指定认证模板下用户的强制认证域为“isp1”。

```
[Router] authentication-profile name p1
[Router-authen-profile-p1] mac-access-profile m1
```

```
[Router-authen-profile-p1] access-domain isp1 force
[Router-authen-profile-p1] quit
```

在接口Eth2/0/0上绑定认证模板“p1”，使能MAC认证。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] authentication-profile p1
[Router-Ethernet2/0/0] quit
```

步骤4 验证配置结果

1. 执行命令**display mac-authen**查看MAC认证的各项配置信息。从显示信息中能够看到接口Eth2/0/0下已使能MAC认证（**MAC address authentication is enabled**）。
2. 用户启动终端后，设备会自动获取用户终端的MAC地址作为用户名和密码进行认证。
3. 用户认证成功后即可访问网络。
4. 用户上线后，管理员可在设备上执行命令**display access-user**查看在线MAC认证用户信息。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10 20
#
authentication-profile name p1
 mac-access-profile m1
 access-domain isp1 force
#
radius-server template rd1
 radius-server shared-key cipher %^%#5Cz2!R*M%NaEr^6.]')L/$!xTKZ<!!!!!!!!!!%^%#
 radius-server authentication 192.168.2.30 1812 weight 80
#
aaa
 authentication-scheme abc
 authentication-mode radius
 domain isp1
 authentication-scheme abc
 radius-server rd1
#
interface Ethernet2/0/0
 port link-type access
 port default vlan 10
 authentication-profile p1
#
interface Ethernet2/0/1
 port link-type access
 port default vlan 20
#
mac-access-profile name m1
#
return
```

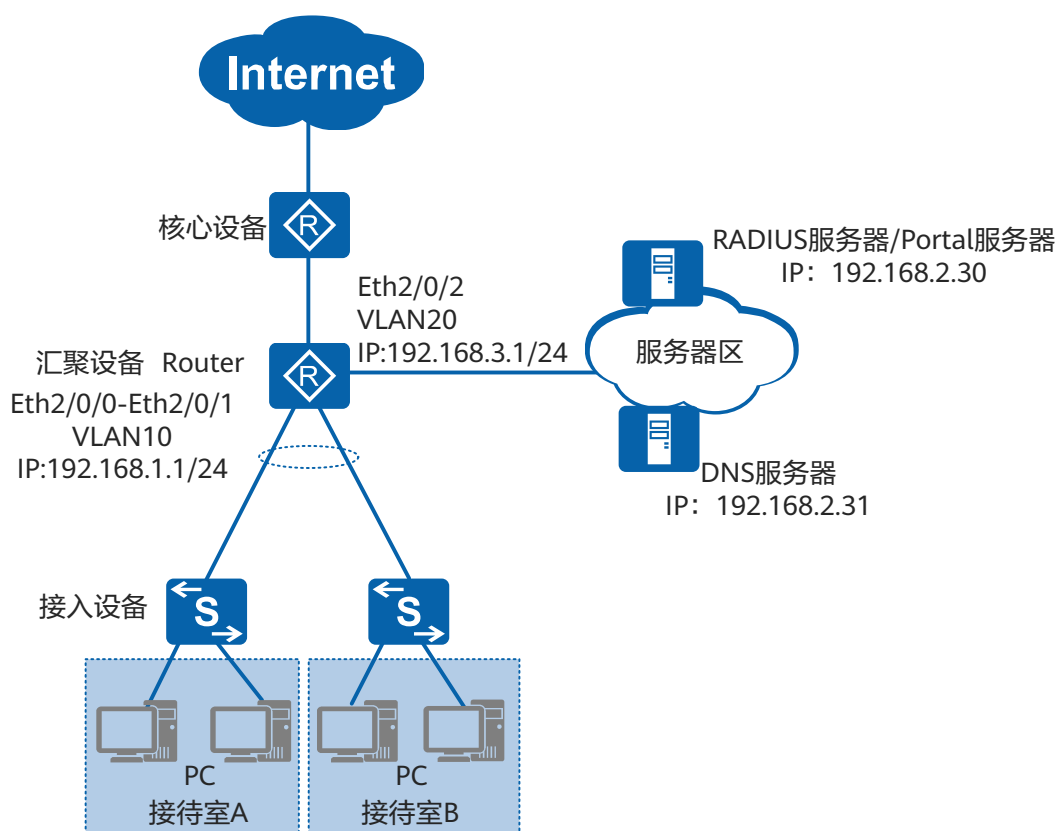
3.7.3 配置外置二层 Portal 认证示例

组网需求

如图3-43所示，某公司接待室需要部署一套身份认证系统，对接入网络的访客终端进行准入控制，确保只有合法用户终端才能接入网络。由于公司接待室的安全控制要求相对适中，为了便于维护，认证点不需要部署太多，所以要求将认证控制点部署在汇聚设备上。

由于Portal认证部署灵活，适用于流动用户；并且，汇聚设备Router与访客终端之间属于二层网络。因此，可在汇聚设备Router上部署二层Portal认证并结合RADIUS服务器（RADIUS服务器与Portal服务器集成在一起），对接入网络的访客终端进行准入控制。

图 3-43 配置外置二层 Portal 认证组网图



配置思路

采用如下的思路在Router上进行配置：

1. 配置网络互通。
2. 配置AAA，实现Router通过RADIUS服务器对接入用户进行身份认证。具体配置包括：配置RADIUS服务器模板、AAA方案以及认证域，并在认证域下绑定RADIUS服务器模板与AAA方案。
3. 配置Portal认证，实现对公司访客区内用户的网络访问权限进行控制。具体配置包括：

- a. 配置Portal服务器模板
- b. 配置Portal接入模板
- c. 配置免认证规则模板
- d. 配置认证模板
- e. 接口下使能Portal认证

说明

配置本举例之前，需确保网络中各设备之间已能互通。

本举例只包括Router上的配置，LAN Switch和RADIUS服务器的配置这里不做相关说明。

配置过程中的共享密钥（RADIUS认证和计费密钥、Portal密钥）、计费周期、端口号等参数，路由器侧与服务器侧必须要配置一致。

操作步骤

步骤1 创建VLAN并配置接口允许通过的VLAN，保证网络通畅

创建VLAN10和VLAN20。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20
```

配置Router与用户连接的接口Eth2/0/0和Eth2/0/1为Access类型接口，并将Eth2/0/0和Eth2/0/1加入VLAN10。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type access
[Router-Ethernet2/0/0] port default vlan 10
[Router-Ethernet2/0/0] quit
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type access
[Router-Ethernet2/0/1] port default vlan 10
[Router-Ethernet2/0/1] quit
```

配置Router连接RADIUS服务器的接口Eth2/0/2为Access类型接口，并将Eth2/0/2加入VLAN20。

```
[Router] interface ethernet 2/0/2
[Router-Ethernet2/0/2] port link-type access
[Router-Ethernet2/0/2] port default vlan 20
[Router-Ethernet2/0/2] quit
```

步骤2 配置接口VLANIF10和VLANIF20的IP地址

```
[Router] interface vlanif 10
[Router-Vlanif10] ip address 192.168.1.1 24
[Router-Vlanif10] quit
```

```
[Router] interface vlanif 20
[Router-Vlanif20] ip address 192.168.3.1 24
[Router-Vlanif20] quit
```

步骤3 配置DHCP服务器为用户终端分配IP地址和告知DNS服务器的IP地址

```
[Router] dhcp enable
[Router] interface vlanif 10
[Router-Vlanif10] dhcp select interface
[Router-Vlanif10] dhcp server dns-list 192.168.2.31
[Router-Vlanif10] quit
```

步骤4 配置到服务器区的静态路由（假设服务器区连接Router的IP地址为192.168.2.1）

```
[Router] ip route-static 192.168.2.0 255.255.255.0 192.168.2.1
```

步骤5 创建并配置RADIUS服务器模板、AAA认证方案以及认证域

创建并配置RADIUS服务器模板“rd1”。

```
[Router] radius-server template rd1
[Router-radius-rd1] radius-server authentication 192.168.2.30 1812
[Router-radius-rd1] radius-server shared-key cipher YsHsjx_202206
[Router-radius-rd1] quit
```

创建AAA方案“abc”并配置认证方式为RADIUS。

```
[Router] aaa
[Router-aaa] authentication-scheme abc
[Router-aaa-authen-abc] authentication-mode radius
[Router-aaa-authen-abc] quit
```

创建认证域“isp1”，并在其上绑定AAA认证方案“abc”与RADIUS服务器模板“rd1”。

```
[Router-aaa] domain isp1
[Router-aaa-domain-isp1] authentication-scheme abc
[Router-aaa-domain-isp1] radius-server rd1
[Router-aaa-domain-isp1] quit
[Router-aaa] quit
```

测试用户是否能够通过RADIUS模板的认证。（已在RADIUS服务器上配置了测试用户test@huawei.com，用户密码YsHsjx_202206。）

```
[Router] test-aaa test@huawei.com YsHsjx_202206 radius-template rd1
Info: Account test succeeded.
```

步骤6 配置Portal认证

配置Portal服务器模板“abc”。

```
[Router] web-auth-server abc
[Router-web-auth-server-abc] server-ip 192.168.2.30
[Router-web-auth-server-abc] port 50200
[Router-web-auth-server-abc] url http://192.168.2.30:8080/webagent
[Router-web-auth-server-abc] shared-key cipher YsHsjx_202206
[Router-web-auth-server-abc] quit
```

配置Portal接入模板“web1”。

```
[Router] portal-access-profile name web1
[Router-portal-access-profile-web1] web-auth-server abc direct
[Router-portal-access-profile-web1] quit
```

配置免认证规则模板“default_free_rule”，放通到DNS服务器的报文。

```
[Router] free-rule-template name default_free_rule
[Router-free-rule-default_free_rule] free-rule 1 destination ip 192.168.2.31 mask 32
[Router-free-rule-default_free_rule] quit
```

 说明

目前在免认证规则模板下配置完免认证规则即可生效，无需在认证模板下绑定免认证规则模板。

配置认证模板“p1”，并在其上绑定Portal接入模板“web1”、指定认证模板下用户的强制认证域为“isp1”、绑定免认证规则模板为“default_free_rule”。

```
[Router] authentication-profile name p1
[Router-authen-profile-p1] portal-access-profile web1
[Router-authen-profile-p1] access-domain isp1 force
[Router-authen-profile-p1] free-rule-template default_free_rule
[Router-authen-profile-p1] quit
```

在接口VLANIF10上绑定认证模板“p1”，使能Portal认证。

```
[Router] interface vlanif 10
[Router-Vlanif10] authentication-profile p1
[Router-Vlanif10] quit
```

步骤7 验证配置结果

1. 执行命令**display portal**和**display web-auth-server configuration**查看外置Portal认证的配置信息。从显示信息中能够看到接口VLANIF10下已绑定Portal服务器模板。（**web-auth-server layer2(direct)**）。
2. 用户打开浏览器输入任意的网络地址后，将会被重定向到Portal认证页面。之后，用户可输入用户名和密码进行认证。
3. 如果用户输入的用户名和密码验证正确，Portal认证页面会显示认证成功信息。用户即可访问网络。
4. 用户上线后，管理员可在设备上执行命令**display access-user**查看在线Portal认证用户信息。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10 20
#
authentication-profile name p1
 portal-access-profile web1
 free-rule-template default_free_rule
 access-domain isp1 force
#
dhcp enable
#
radius-server template rd1
 radius-server shared-key cipher %^%#5Cz2!R*M%NaEr^6.]')L/$!!xTKZ<!!!!!!%^%#
 radius-server authentication 192.168.2.30 1812 weight 80
#
free-rule-template name default_free_rule
 free-rule 1 destination ip 192.168.2.31 mask 255.255.255.255
#
web-auth-server abc
 server-ip 192.168.2.30
 port 50200
 shared-key cipher %^%#'=oP,*KKUSPqB7M5Cf2G)!!t/&,$!!!!!!%^%#
 url http://192.168.2.30:8080/webagent
#
portal-access-profile name web1
 web-auth-server abc direct
#
aaa
 authentication-scheme abc
 authentication-mode radius
 domain isp1
 authentication-scheme abc
 radius-server rd1
#
interface Vlanif10
 ip address 192.168.1.1 255.255.255.0
 authentication-profile p1
 dhcp select interface
 dhcp server dns-list 192.168.2.31
#
interface Vlanif20
 ip address 192.168.3.1 255.255.255.0
#
interface Ethernet2/0/0
 port link-type access
 port default vlan 10
```



```
#
interface Ethernet2/0/1
port link-type access
port default vlan 10
#
interface Ethernet2/0/2
port link-type access
port default vlan 20
#
ip route-static 192.168.2.0 255.255.255.0 192.168.2.1
#
return
```

3.7.4 配置外置二层 Portal 认证示例（使用重定向参数）

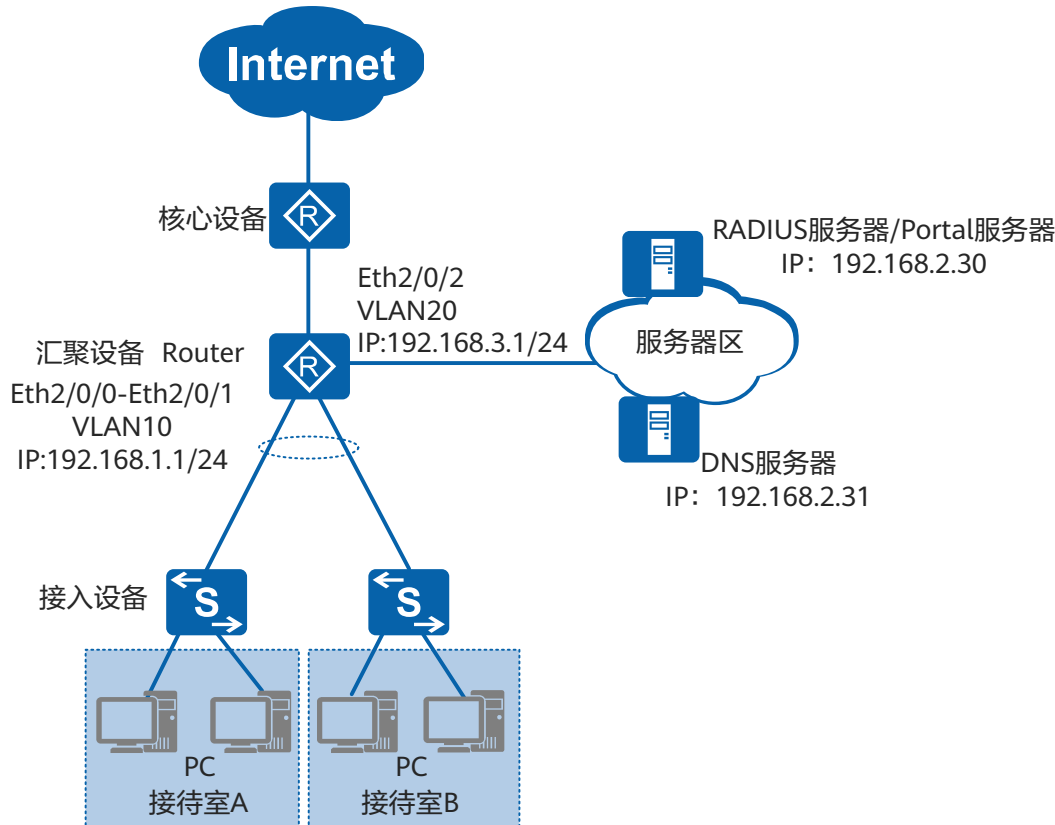
组网需求

如图3-44所示，某公司接待室需要部署一套身份认证系统，对接入网络的访客终端进行准入控制，确保只有合法用户终端才能接入网络。由于公司接待室的安全控制要求相对适中，为了便于维护，认证点不需要部署太多，所以要求将认证控制点部署在汇聚设备上。

由于Portal认证部署灵活，适用于流动用户；并且，汇聚设备Router与访客终端之间属于二层网络。因此，可在汇聚设备Router上部署二层Portal认证并结合RADIUS服务器（RADIUS服务器与Portal服务器集成在一起），对接入网络的访客终端进行准入控制。

Portal认证采用重定向URL的方式指定URL中携带的参数，使得Portal服务器能够根据URL中的参数获取到用户终端的信息，根据用户终端信息，可以满足为不同用户提供不同的Web认证界面。

图 3-44 配置外置二层 Portal 认证组网图



配置思路

采用如下的思路在Router上进行配置：

1. 配置网络互通。
2. 配置AAA，实现Router通过RADIUS服务器对接入用户进行身份认证。具体配置包括：配置RADIUS服务器模板、AAA方案以及认证域，并在认证域下绑定RADIUS服务器模板与AAA方案。
3. 配置URL模板，配置指向Portal服务器的重定向URL和携带的参数。
4. 配置Portal认证，实现对公司访客区内用户的网络访问权限进行控制。具体配置包括：
 - a. 配置Portal服务器模板
 - b. 配置Portal接入模板
 - c. 配置免认证规则模板
 - d. 配置认证模板
 - e. 接口下使能Portal认证

说明

配置本举例之前，需确保网络中各设备之间已能互通。

本举例只包括Router上的配置，LAN Switch和RADIUS服务器的配置这里不做相关说明。

配置过程中的共享密钥（RADIUS认证和计费密钥、Portal密钥）、计费周期、端口号等参数，路由器侧与服务器侧必须要配置一致。

操作步骤

步骤1 创建VLAN并配置接口允许通过的VLAN，保证网络通畅

创建VLAN10和VLAN20。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20
```

配置Router与用户连接的接口Eth2/0/0和Eth2/0/1为Access类型接口，并将Eth2/0/0和Eth2/0/1加入VLAN10。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type access
[Router-Ethernet2/0/0] port default vlan 10
[Router-Ethernet2/0/0] quit
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type access
[Router-Ethernet2/0/1] port default vlan 10
[Router-Ethernet2/0/1] quit
```

配置Router连接RADIUS服务器的接口Eth2/0/2为Access类型接口，并将Eth2/0/2加入VLAN20。

```
[Router] interface ethernet 2/0/2
[Router-Ethernet2/0/2] port link-type access
[Router-Ethernet2/0/2] port default vlan 20
[Router-Ethernet2/0/2] quit
```

步骤2 配置接口VLANIF10和VLANIF20的IP地址

```
[Router] interface vlanif 10
[Router-Vlanif10] ip address 192.168.1.1 24
[Router-Vlanif10] quit
[Router] interface vlanif 20
[Router-Vlanif20] ip address 192.168.3.1 24
[Router-Vlanif20] quit
```

步骤3 配置DHCP服务器为用户终端分配IP地址和告知DNS服务器的IP地址

```
[Router] dhcp enable
[Router] interface vlanif 10
[Router-Vlanif10] dhcp select interface
[Router-Vlanif10] dhcp server dns-list 192.168.2.31
[Router-Vlanif10] quit
```

步骤4 配置到服务器区的静态路由（假设服务器区连接Router的IP地址为192.168.2.1）

```
[Router] ip route-static 192.168.2.0 255.255.255.0 192.168.2.1
```

步骤5 创建并配置RADIUS服务器模板、AAA认证方案以及认证域

创建并配置RADIUS服务器模板“rd1”。

```
[Router] radius-server template rd1
[Router-radius-rd1] radius-server authentication 192.168.2.30 1812
[Router-radius-rd1] radius-server shared-key cipher YsHsjx_202206
[Router-radius-rd1] quit
```

创建AAA方案“abc”并配置认证方式为RADIUS。

```
[Router] aaa
[Router-aaa] authentication-scheme abc
[Router-aaa-authen-abc] authentication-mode radius
[Router-aaa-authen-abc] quit
```

创建认证域“isp1”，并在其上绑定AAA认证方案“abc”与RADIUS服务器模板“rd1”。

```
[Router-aaa] domain isp1
[Router-aaa-domain-isp1] authentication-scheme abc
[Router-aaa-domain-isp1] radius-server rd1
[Router-aaa-domain-isp1] quit
[Router-aaa] quit
```

测试用户是否能够通过RADIUS模板的认证。（已在RADIUS服务器上配置了测试用户test@huawei.com，用户密码YsHsjx_202206。）

```
[Router] test-aaa test@huawei.com YsHsjx_202206 radius-template rd1
Info: Account test succeeded.
```

步骤6 配置URL模板，配置指向Portal服务器的重定向URL，并指定URL中携带的参数为用户IP地址和用户MAC地址。

```
[Router] url-template name url1
[Router-url-template-url1] url https://10.23.200.1:8445/portal
[Router-url-template-url1] url-parameter user-ipaddress userip user-mac usermac
[Router-url-template-url1] quit
```

 说明

配置重定向URL携带哪些参数取决于Portal服务器要求，此处仅为示例，即本案例中Portal服务器要求重定向参数携带用户IP地址和用户MAC地址，**user-ipaddress**和**user-mac**为当前设备识别用户IP地址和用户MAC地址的参数，**userip**和**usermac**为Portal服务器识别用户IP地址和用户MAC地址的参数，不同服务器对应的参数可能存在差异。

步骤7 配置Portal认证

配置Portal服务器模板“abc”。

```
[Router] web-auth-server abc
[Router-web-auth-server-abc] server-ip 10.23.200.1
[Router-web-auth-server-abc] port 50200
```

```
[Router-web-auth-server-abc] url-template url1
[Router-web-auth-server-abc] shared-key cipher YsHsjx_202206
[Router-web-auth-server-abc] quit
```

配置Portal接入模板“web1”。

```
[Router] portal-access-profile name web1
[Router-portal-access-profile-web1] web-auth-server abc direct
[Router-portal-access-profile-web1] quit
```

配置免认证规则模板“default_free_rule”，放通到DNS服务器的报文。

```
[Router] free-rule-template name default_free_rule
[Router-free-rule-default_free_rule] free-rule 1 destination ip 192.168.2.31 mask 32
[Router-free-rule-default_free_rule] quit
```

说明

目前在免认证规则模板下配置完免认证规则即可生效，无需在认证模板下绑定免认证规则模板。

配置认证模板“p1”，并在其上绑定Portal接入模板“web1”、指定认证模板下用户的强制认证域为“isp1”、绑定免认证规则模板为“default_free_rule”。

```
[Router] authentication-profile name p1
[Router-authen-profile-p1] portal-access-profile web1
[Router-authen-profile-p1] access-domain isp1 force
[Router-authen-profile-p1] free-rule-template default_free_rule
[Router-authen-profile-p1] quit
```

在接口VLANIF10上绑定认证模板“p1”，使能Portal认证。

```
[Router] interface vlanif 10
[Router-Vlanif10] authentication-profile p1
[Router-Vlanif10] quit
```

步骤8 验证配置结果

1. 执行命令**display portal**和**display web-auth-server configuration**查看外置Portal认证的配置信息。从显示信息中能够看到接口VLANIF10下已绑定Portal服务器模板。（**web-auth-server layer2(direct)**）。
2. 用户打开浏览器输入任意的网络地址后，将会被重定向到Portal认证页面。之后，用户可输入用户名和密码进行认证。
3. 如果用户输入的用户名和密码验证正确，Portal认证页面会显示认证成功信息。用户即可访问网络。
4. 用户上线后，管理员可在设备上执行命令**display access-user**查看在线Portal认证用户信息。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10 20
#
authentication-profile name p1
portal-access-profile web1
free-rule-template default_free_rule
access-domain isp1 force
#
dhcp enable
#
```

```
radius-server template rd1
radius-server shared-key cipher %^%#5Cz2!R*M%NaEr^6.]')L/$!!xTKZ<!!!!!!%^^#
radius-server authentication 192.168.2.30 1812 weight 80
#
free-rule-template name default_free_rule
free-rule 1 destination ip 192.168.2.31 mask 255.255.255.255
#
url-template url1
url https://10.23.200.1:8445/portal
url-parameter user-ipaddress userip user-mac usermac
#
web-auth-server abc
server-ip 10.23.200.1
port 50200
shared-key cipher %^%#'=oP;*.KKUSPqB7M5Cf2G)!!t/&,$!!!!!!!!%^^#
url-template url1
#
portal-access-profile name web1
web-auth-server abc direct
#
aaa
authentication-scheme abc
authentication-mode radius
domain isp1
authentication-scheme abc
radius-server rd1
#
interface Vlanif10
ip address 192.168.1.1 255.255.255.0
authentication-profile p1
dhcp select interface
dhcp server dns-list 192.168.2.31
#
interface Vlanif20
ip address 192.168.3.1 255.255.255.0
#
interface Ethernet2/0/0
port link-type access
port default vlan 10
#
interface Ethernet2/0/1
port link-type access
port default vlan 10
#
interface Ethernet2/0/2
port link-type access
port default vlan 20
#
ip route-static 192.168.2.0 255.255.255.0 192.168.2.1
#
return
```

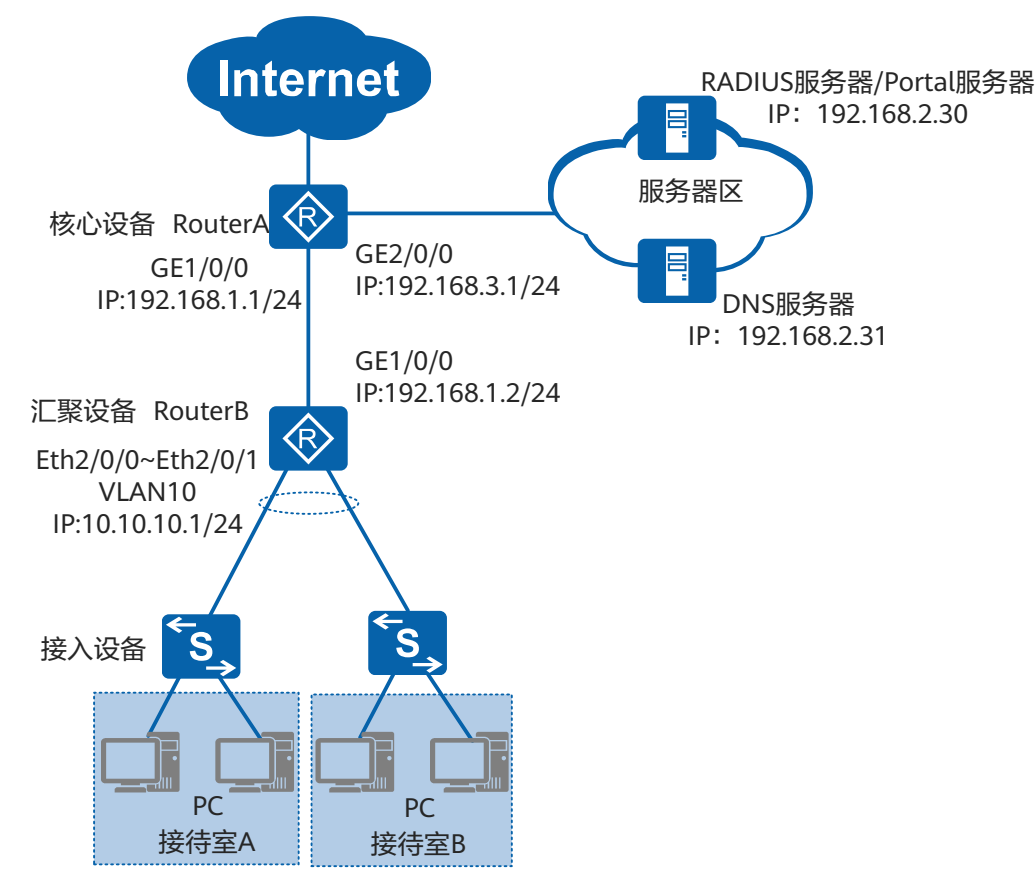
3.7.5 配置外置三层 Portal 认证示例

组网需求

如图3-45所示，某公司接待室需要部署一套身份认证系统，对接入网络的访客终端进行准入控制，确保只有合法用户终端才能接入网络。为了便于以后网络改造，节省投资，要求认证控制点部署在核心设备上。

由于Portal认证部署灵活，适用于流动用户；并且，核心设备RouterA与访客终端之间跨三层网络。因此，可在核心设备RouterA上部署三层Portal认证并结合RADIUS服务器（RADIUS服务器与Portal服务器集成在一起），对接入网络的访客终端进行准入控制。

图 3-45 配置外置三层 Portal 认证组网图



配置思路

采用如下的思路在Router上进行配置：

1. 配置网络互通。
2. 配置AAA，实现RouterA通过RADIUS服务器对接入用户进行身份认证。具体配置包括：配置RADIUS服务器模板、AAA方案以及认证域，并在认证域下绑定RADIUS服务器模板与AAA方案。
3. 配置Portal认证，实现对公司访客区内用户的网络访问权限进行控制。具体配置包括：
 - a. 配置Portal服务器模板
 - b. 配置Portal接入模板
 - c. 配置免认证规则模板
 - d. 配置认证模板
 - e. 接口下使能Portal认证

 说明

配置本举例之前，需确保网络中各设备之间已能互通。

本举例只包括Router上的配置，LAN Switch和RADIUS服务器的配置这里不做相关说明。

配置过程中的共享密钥（RADIUS认证和计费密钥、Portal密钥）、计费周期、端口号等参数，路由器侧与服务器侧必须要配置一致。

操作步骤

步骤1 配置RouterB，保证网络互通

创建VLAN10。

```
<Huawei> system-view
[Huawei] sysname RouterB
[RouterB] vlan batch 10
```

配置RouterB与用户连接的接口Eth2/0/0和Eth2/0/1为Access类型接口，并将Eth2/0/0和Eth2/0/1加入VLAN10。

```
[RouterB] interface ethernet 2/0/0
[RouterB-Ethernet2/0/0] port link-type access
[RouterB-Ethernet2/0/0] port default vlan 10
[RouterB-Ethernet2/0/0] quit
[RouterB] interface ethernet 2/0/1
[RouterB-Ethernet2/0/1] port link-type access
[RouterB-Ethernet2/0/1] port default vlan 10
[RouterB-Ethernet2/0/1] quit
```

配置RouterB连接RouterA的接口GE1/0/0的IP地址。

```
[RouterB] interface gigabitEthernet 1/0/0
[RouterB-GigabitEthernet1/0/0] ip address 192.168.1.2 24
[RouterB-GigabitEthernet1/0/0] quit
```

配置接口VLANIF10的IP地址并配置其作为DHCP中继。

```
[RouterB] dhcp enable
[RouterB] interface vlanif 10
[RouterB-Vlanif10] ip address 10.10.10.1 24
[RouterB-Vlanif10] dhcp select relay
[RouterB-Vlanif10] dhcp relay server-ip 192.168.1.1
[RouterB-Vlanif10] quit
```

配置缺省路由。

```
[RouterB] ip route-static 0.0.0.0 0.0.0.0 192.168.1.1
```

步骤2 配置RouterA，保证网络互通

配置RouterA与RouterB连接的接口GE1/0/0的IP地址。

```
[RouterA] interface gigabitEthernet 1/0/0
[RouterA-GigabitEthernet1/0/0] ip address 192.168.1.1 24
[RouterA-GigabitEthernet1/0/0] quit
```

配置RouterA与服务器区连接的接口GE2/0/0的IP地址。

```
[RouterA] interface gigabitEthernet 2/0/0
[RouterA-GigabitEthernet2/0/0] ip address 192.168.3.1 24
[RouterA-GigabitEthernet2/0/0] quit
```

配置DHCP服务器功能，为用户终端分配IP地址和告知DNS服务器的IP地址、网关地址。

```
[RouterA] dhcp enable
[RouterA] ip pool pool1
```

```
[RouterA-ip-pool-pool1] network 10.10.10.0 mask 24
[RouterA-ip-pool-pool1] gateway-list 10.10.10.1
[RouterA-ip-pool-pool1] dns-list 192.168.2.31
[RouterA-ip-pool-pool1] quit
[RouterA] interface gigabitEthernet 1/0/0
[RouterA-GigabitEthernet1/0/0] dhcp select global
[RouterA-GigabitEthernet1/0/0] quit
```

配置RouterA到用户终端和到服务器区的静态路由（假设服务器区连接Router的IP地址为192.168.2.1）。

```
[RouterA] ip route-static 10.10.10.0 255.255.255.0 192.168.1.2
[RouterA] ip route-static 192.168.2.0 255.255.255.0 192.168.2.1
```

步骤3 创建并配置RADIUS服务器模板、AAA认证方案以及认证域

创建并配置RADIUS服务器模板“rd1”。

```
[RouterA] radius-server template rd1
[RouterA-radius-rd1] radius-server authentication 192.168.2.30 1812
[RouterA-radius-rd1] radius-server shared-key cipher YsHsjx_202206
[RouterA-radius-rd1] quit
```

创建AAA方案“abc”并配置认证方式为RADIUS。

```
[RouterA] aaa
[RouterA-aaa] authentication-scheme abc
[RouterA-aaa-authen-abc] authentication-mode radius
[RouterA-aaa-authen-abc] quit
```

创建认证域“isp1”，并在其上绑定AAA认证方案“abc”与RADIUS服务器模板“rd1”。

```
[RouterA-aaa] domain isp1
[RouterA-aaa-domain-isp1] authentication-scheme abc
[RouterA-aaa-domain-isp1] radius-server rd1
[RouterA-aaa-domain-isp1] quit
[RouterA-aaa] quit
```

测试用户是否能够通过RADIUS模板的认证。（已在RADIUS服务器上配置了测试用户test@huawei.com，用户密码YsHsjx_202206。）

```
[RouterA] test-aaa test@huawei.com YsHsjx_202206 radius-template rd1
Info: Account test succeeded.
```

步骤4 配置Portal认证

配置Portal服务器模板“abc”。

```
[RouterA] web-auth-server abc
[RouterA-web-auth-server-abc] server-ip 192.168.2.30
[RouterA-web-auth-server-abc] port 50200
[RouterA-web-auth-server-abc] url http://192.168.2.30:8080/webagent
[RouterA-web-auth-server-abc] shared-key cipher YsHsjx_202206
[RouterA-web-auth-server-abc] quit
```

配置Portal接入模板“web1”。

```
[RouterA] portal-access-profile name web1
[RouterA-portal-access-profile-web1] web-auth-server abc layer3
[RouterA-portal-access-profile-web1] quit
```

配置免认证规则模板“default_free_rule”，放通到DNS服务器和DHCP服务器的报文。

```
[RouterA] free-rule-template name default_free_rule
[RouterA-free-rule-default_free_rule] free-rule 1 destination ip 192.168.2.31 mask 32
[RouterA-free-rule-default_free_rule] free-rule 2 destination ip 192.168.1.1 mask 32
[RouterA-free-rule-default_free_rule] quit
```


说明

目前在免认证规则模板下配置完免认证规则即可生效，无需在认证模板下绑定免认证规则模板。

配置认证模板“p1”，并在其上绑定Portal接入模板“web1”、指定认证模板下用户的强制认证域为“isp1”、绑定免认证规则模板为“default_free_rule”。

```
[RouterA] authentication-profile name p1
[RouterA-authen-profile-p1] portal-access-profile web1
[RouterA-authen-profile-p1] access-domain isp1 force
[RouterA-authen-profile-p1] free-rule-template default_free_rule
[RouterA-authen-profile-p1] quit
```

在接口GE1/0/0上绑定认证模板“p1”，使能Portal认证。

```
[RouterA] interface gigabitEthernet 1/0/0
[RouterA-GigabitEthernet1/0/0] authentication-profile p1
[RouterA-GigabitEthernet1/0/0] quit
```

步骤5 验证配置结果

1. 在RouterA上，执行命令**display portal**和**display web-auth-server configuration**查看外置Portal认证的配置信息。从显示信息中能够看到接口GE1/0/0下已绑定Portal服务器模板。（**web-auth-server layer3**）。
2. 用户打开浏览器输入任意的网络地址后，将会被重定向到Portal认证页面。之后，用户可输入用户名和密码进行认证。
3. 如果用户输入的用户名和密码验证正确，Portal认证页面会显示认证成功信息。用户即可访问网络。
4. 用户上线后，管理员可在RouterA上执行命令**display access-user**查看在线Portal认证用户信息。

----结束

配置文件

• RouterA的配置文件

```
#
sysname RouterA
#
authentication-profile name p1
portal-access-profile web1
free-rule-template default_free_rule
access-domain isp1 force
#
dhcp enable
#
radius-server template rd1
radius-server shared-key cipher %^%#5Cz2!R*M%NaEr^6.]')L/$!!xTKZ<!!!!!!%^^%#
radius-server authentication 192.168.2.30 1812 weight 80
#
free-rule-template name default_free_rule
free-rule 1 destination ip 192.168.3.31 mask 255.255.255.255
free-rule 2 destination ip 192.168.1.1 mask 255.255.255.255
#
web-auth-server abc
server-ip 192.168.2.30
port 50200
shared-key cipher %^%#'=oP;*.KKUSPqB7M5Cf2G)!!!!/&,$!!!!!!!!!!%^^%#
url http://192.168.2.30:8080/webagent
#
portal-access-profile name web1
web-auth-server abc layer3
#
```

```
ip pool pool1
gateway-list 10.10.10.1
network 10.10.10.0 mask 255.255.255.0
dns-list 192.168.2.31
#
aaa
authentication-scheme abc
authentication-mode radius
domain isp1
authentication-scheme abc
radius-server rd1
#
interface GigabitEthernet1/0/0
ip address 192.168.1.1 255.255.255.0
authentication-profile p1
dhcp select global
#
interface GigabitEthernet2/0/0
ip address 192.168.3.1 255.255.255.0
#
ip route-static 10.10.10.0 255.255.255.0 192.168.1.2
ip route-static 192.168.2.0 255.255.255.0 192.168.2.1
#
return
```

- RouterB的配置文件

```
#
sysname RouterB
#
vlan batch 10
#
dhcp enable
#
interface Vlanif10
ip address 10.10.10.1 255.255.255.0
dhcp select relay
dhcp relay server-ip 192.168.1.1
#
interface Ethernet2/0/0
port link-type access
port default vlan 10
#
interface Ethernet2/0/1
port link-type access
port default vlan 10
#
interface GigabitEthernet1/0/0
ip address 192.168.1.2 255.255.255.0
#
ip route-static 0.0.0.0 0.0.0.0 192.168.1.1
#
return
```

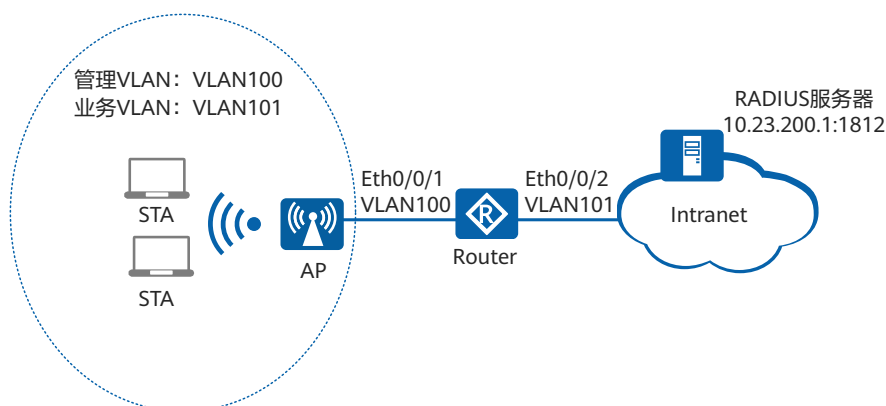
3.7.6 配置 802.1X 认证示例（AAA 采用 RADIUS 方式）

组网需求

如图3-46所示，某企业Router直连AP，通过WLAN部署，提供名为“wlan-net”的无线网络方便员工接入。同时，Router作为DHCP服务器为无线用户提供10.23.101.0/24网段的IP地址。

由于无线网络开放性的特点，如果无线网络不采取适当的接入控制，企业信息就存在安全风险。为了满足企业的高安全性需求，只允许指定的终端设备和用户接入。通过RADIUS服务器，对使用终端设备的用户进行802.1X认证。

图 3-46 配置 802.1X 认证组网图



配置思路

1. 配置WLAN基本业务，实现Router与上下游网络互通和AP上线。
2. 配置RADIUS认证参数。
3. 配置802.1X接入模板。
4. 配置认证模板，管理NAC认证的相关配置。
5. 配置WLAN业务参数，在VAP模板下绑定安全策略模板和认证模板等，对访问WLAN网络的STA进行接入控制。

操作步骤

步骤1 配置Router，使AP与Router之间能够传输CAPWAP报文

配置Router，将接口Eth0/0/1加入VLAN100（管理VLAN）。

说明

本示例的业务数据转发方式采用隧道转发。如果用户的数据转发方式为直接转发，建议在Router连接AP的接口Eth0/0/1上配置端口隔离，如果不配置端口隔离，可能会在VLAN内产生不必要的广播报文，或者导致不同AP间的WLAN用户二层互通的问题。

隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 100 101
[Router] interface ethernet 0/0/1
[Router-Ethernet0/0/1] port link-type trunk
[Router-Ethernet0/0/1] port trunk pvid vlan 100
[Router-Ethernet0/0/1] port trunk allow-pass vlan 100
[Router-Ethernet0/0/1] quit
```

步骤2 配置Router与上层网络设备互通

配置Router上行接口Eth0/0/2加入VLAN101（业务VLAN）。

```
[Router] interface ethernet 0/0/2
[Router-Ethernet0/0/2] port link-type trunk
[Router-Ethernet0/0/2] port trunk allow-pass vlan 101
[Router-Ethernet0/0/2] quit
```

步骤3 配置Router作为DHCP服务器，为STA和AP分配IP地址

配置基于接口地址池的DHCP服务器，其中，VLANIF100接口为AP提供IP地址，VLANIF101为STA提供IP地址。

说明

DNS服务器地址请根据实际需要配置。常用配置方法如下：

- 接口地址池场景，需要在VLANIF接口视图下执行命令**dhcp server dns-list ip-address &<1-8>**。
- 全局地址池场景，需要在IP地址池视图下执行命令**dns-list ip-address &<1-8>**。

```
[Router] dhcp enable
[Router] interface vlanif 100
[Router-Vlanif100] ip address 10.23.100.1 24
[Router-Vlanif100] dhcp select interface
[Router-Vlanif100] quit
[Router] interface vlanif 101
[Router-Vlanif101] ip address 10.23.101.1 24
[Router-Vlanif101] dhcp select interface
[Router-Vlanif101] quit
```

步骤4 配置Router到服务器区的路由（假设与Router相连的上游设备的IP地址为10.23.101.2）

```
[Router] ip route-static 10.23.200.0 255.255.255.0 10.23.101.2
```

步骤5 配置AP上线

创建AP组，用于将相同配置的AP都加入同一AP组中。

```
[Router] wlan ac
[Router-wlan-view] ap-group name ap-group1
[Router-wlan-ap-group-ap-group1] quit
```

创建域管理模板，在域管理模板下配置Router的国家码并在AP组下引用域管理模板。

```
[Router-wlan-view] regulatory-domain-profile name domain1
[Router-wlan-regulate-domain-domain1] country-code cn
[Router-wlan-regulate-domain-domain1] quit
[Router-wlan-view] ap-group name ap-group1
[Router-wlan-ap-group-ap-group1] regulatory-domain-profile domain1
Warning: This operation may cause AP reset. If the country code changes, it will clear channel, power and antenna gain configuration s of the radio, Whether to continue? [Y/N]:y
[Router-wlan-ap-group-ap-group1] quit
[Router-wlan-view] quit
```

配置Router的源接口。

```
[Router] capwap source interface vlanif 100
```

在Router上离线导入AP，并将AP加入AP组“ap-group1”中。假设AP的MAC地址为00e0-fc76-e360，并且根据AP的部署位置为AP配置名称，便于从名称上就能够了解AP的部署位置。例如MAC地址为00e0-fc76-e360的AP部署在1号区域，命名此AP为area_1。

说明

ap auth-mode命令缺省情况下为MAC认证，如果之前没有修改其缺省配置，可以不用执行**ap auth-mode mac-auth**命令。

举例中使用的AP为AP5030DN，具有射频0和射频1两个射频。AP5030DN的射频0为2.4GHz射频，射频1为5GHz射频。

```
[Router] wlan ac
[Router-wlan-view] ap auth-mode mac-auth
[Router-wlan-view] ap-id 0 ap-mac 00e0-fc76-e360
[Router-wlan-ap-0] ap-name area_1
[Router-wlan-ap-0] ap-group ap-group1
```

```
Warning: This operation may cause AP reset. If the country code changes, it will clear channel, power and antenna gain configuration s of the radio, Whether to continue? [Y/N]:y
[Router-wlan-ap-0] quit
[Router-wlan-view] quit
```

将AP上电后，当执行命令**display ap all**查看到AP的“State”字段为“nor”时，表示AP正常上线。

```
[Router] display ap all
Total AP information:nor : normal          [1]
-----
ID  MAC          Name  Group  IP          Type          State STA Uptime
-----
0   00e0-fcf6-e360 area_1 ap-group1 10.23.100.254 AP6010DN-AGN  nor  0   4H:49M:11S
-----
Total: 1
```

步骤6 配置RADIUS服务器模板、RADIUS认证方案和RADIUS计费方案

 说明

请确保RADIUS服务器地址、端口号、共享密钥配置正确，并且和RADIUS服务器保持一致。

配置RADIUS服务器模板。

```
[Router] radius-server template radius_huawei
[Router-radius-radius_huawei] radius-server authentication 10.23.200.1 1812
[Router-radius-radius_huawei] radius-server accounting 10.23.200.1 1813
[Router-radius-radius_huawei] radius-server shared-key cipher YsHsjx_202206
[Router-radius-radius_huawei] quit
```

配置RADIUS方式的认证方案。

```
[Router] aaa
[Router-aaa] authentication-scheme radius_huawei
[Router-aaa-authen-radius_huawei] authentication-mode radius
[Router-aaa-authen-radius_huawei] quit
```

配置RADIUS方式的计费方案。

```
[Router-aaa] accounting-scheme scheme1
[Router-aaa-accounting-scheme1] accounting-mode radius
[Router-aaa-accounting-scheme1] accounting realtime 15
[Router-aaa-accounting-scheme1] quit
[Router-aaa] quit
```

 说明

- 以设备与iMaster NCE控制器对接为例，计费功能并非真实意义上的计算费用，而是通过计费报文维护终端的在线信息。
- **accounting realtime**命令用来配置实时计费间隔。实时计费间隔的取值对设备和RADIUS服务器的性能有要求，实时计费间隔的取值越小，对设备和RADIUS服务器的性能就越高。请根据用户数设置实时计费间隔。

用户数	实时计费间隔
1 ~ 99	3min
100 ~ 499	6min
500 ~ 999	12min
≥1000	≥15min

步骤7 配置802.1X接入模板“d1” **说明**

802.1X接入模板默认采用EAP认证方式。请确保RADIUS服务器支持EAP协议，否则无法处理802.1X认证请求。

```
[Router] dot1x-access-profile name d1
[Router-dot1x-access-profile-d1] quit
```

步骤8 配置认证模板“p1”

```
[Router] authentication-profile name p1
[Router-authentication-profile-p1] dot1x-access-profile d1
[Router-authentication-profile-p1] authentication-scheme radius_huawei
[Router-authentication-profile-p1] accounting-scheme scheme1
[Router-authentication-profile-p1] radius-server radius_huawei
[Router-authentication-profile-p1] quit
```

步骤9 配置WLAN业务参数

创建名为“wlan-security”的安全模板，并配置安全策略。

```
[Router] wlan ac
[Router-wlan-view] security-profile name wlan-security
[Router-wlan-sec-prof-wlan-security] security wpa2 dot1x aes
[Router-wlan-sec-prof-wlan-security] quit
```

创建名为“wlan-ssid”的SSID模板，并配置SSID名称为“wlan-net”。

```
[Router-wlan-view] ssid-profile name wlan-ssid
[Router-wlan-ssid-prof-wlan-ssid] ssid wlan-net
[Router-wlan-ssid-prof-wlan-ssid] quit
```

创建名为“wlan-vap”的VAP模板，配置业务数据转发模式、业务VLAN，并且引用安全模板、SSID模板和认证模板。

```
[Router-wlan-view] vap-profile name wlan-vap
[Router-wlan-vap-prof-wlan-vap] forward-mode tunnel
[Router-wlan-vap-prof-wlan-vap] service-vlan vlan-id 101
[Router-wlan-vap-prof-wlan-vap] security-profile wlan-security
[Router-wlan-vap-prof-wlan-vap] ssid-profile wlan-ssid
[Router-wlan-vap-prof-wlan-vap] authentication-profile p1
[Router-wlan-vap-prof-wlan-vap] quit
```

配置AP组引用VAP模板，AP上射频0和射频1都使用VAP模板“wlan-vap”的配置。

```
[Router-wlan-view] ap-group name ap-group1
[Router-wlan-ap-group-ap-group1] vap-profile wlan-vap wlan 1 radio 0
[Router-wlan-ap-group-ap-group1] vap-profile wlan-vap wlan 1 radio 1
[Router-wlan-ap-group-ap-group1] quit
```

步骤10 配置AP射频的信道和功率 **说明**

射频的信道和功率自动调优功能默认开启，如果不关闭此功能则会导致手动配置不生效。举例中AP射频的信道和功率仅为示例，实际配置中请根据AP的国家码和网规结果进行配置。

关闭AP射频0的信道和功率自动调优功能，并配置AP射频0的信道和功率。

```
[Router-wlan-view] ap-id 0
[Router-wlan-ap-0] radio 0
[Router-wlan-radio-0/0] calibrate auto-channel-select disable
[Router-wlan-radio-0/0] calibrate auto-tpower-select disable
[Router-wlan-radio-0/0] channel 20mhz 6
Warning: This action may cause service interruption. Continue?[Y/N]y
[Router-wlan-radio-0/0] eirp 127
[Router-wlan-radio-0/0] quit
```

关闭AP射频1的信道和功率自动调优功能，并配置AP射频1的信道和功率。

```
[Router-wlan-ap-0] radio 1
[Router-wlan-radio-0/1] calibrate auto-channel-select disable
[Router-wlan-radio-0/1] calibrate auto-tpower-select disable
[Router-wlan-radio-0/1] channel 20mhz 149
Warning: This action may cause service interruption. Continue?[Y/N]y
[Router-wlan-radio-0/1] eirp 127
[Router-wlan-radio-0/1] quit
[Router-wlan-ap-0] quit
[Router-wlan-view]
```

步骤11 提交配置

在WLAN视图下的配置结束后执行**commit**命令进行下发到AP。

```
[Router-wlan-view] commit all
```

步骤12 检查配置结果

完成配置后，用户可通过无线终端搜索到SSID为**wlan-net**的无线网络。用户使用公司指定的终端设备时，先对终端设备进行MAC认证，认证成功后再对使用终端设备的用户进行802.1X认证。用户使用非公司指定的终端设备时，无法进行认证。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 100 to 101
#
authentication-profile name p1
dot1x-access-profile d1
authentication-scheme radius_huawei
accounting-scheme scheme1
radius-server radius_huawei
#
dhcp enable
#
radius-server template radius_huawei
radius-server shared-key cipher %^%#Oc6_BMCw#9gZ2@SMVtk!PAC6>Ou*eLW/"qLp+f#$%^%#
radius-server authentication 10.23.200.1 1812 weight 80
radius-server accounting 10.23.200.1 1813 weight 80
#
aaa
authentication-scheme radius_huawei
authentication-mode radius
accounting-scheme scheme1
accounting-mode radius
accounting realtime 15
#
interface Vlanif100
ip address 10.23.100.1 255.255.255.0
dhcp select interface
#
interface Vlanif101
ip address 10.23.101.1 255.255.255.0
dhcp select interface
#
interface Ethernet0/0/1
port link-type trunk
port trunk pvid vlan 100
port trunk allow-pass vlan 100
#
interface Ethernet0/0/2
port link-type trunk
```

```
port trunk allow-pass vlan 101
#
ip route-static 10.23.200.0 255.255.255.0 10.23.101.2
#
capwap source interface vlanif100
#
wlan
security-profile name wlan-security
security wpa2 dot1x aes
ssid-profile name wlan-ssid
ssid wlan-net
vap-profile name wlan-vap
forward-mode tunnel
service-vlan vlan-id 101
ssid-profile wlan-ssid
security-profile wlan-security
authentication-profile p1
regulatory-domain-profile name domain1
ap-group name ap-group1
regulatory-domain-profile domain1
radio 0
vap-profile wlan-vap wlan 1
radio 1
vap-profile wlan-vap wlan 1
ap-id 0 ap-mac 00e0-fc76-e360
ap-name area_1
ap-group ap-group1
radio 0
channel 20mhz 6
eirp 127
calibrate auto-channel-select disable
calibrate auto-txpower-select disable
radio 1
channel 20mhz 149
eirp 127
calibrate auto-channel-select disable
calibrate auto-txpower-select disable
#
dot1x-access-profile name d1
#
return
```

3.8 NAC FAQ

3.8.1 802.1x 用户动态 VLAN 什么情况下才能生效

基于端口方式（port-based）认证情况下，当用户接入的端口类型为hybrid且为untagged方式时，动态VLAN生效。

3.8.2 display access-user 时，为何有时不能显示 802.1x 用户的 IP 地址

用户认证上线后，设备捕获该用户的ARP报文，并从中学习到用户的IP地址。如果用户没有发出ARP报文，那么设备上就无法学习、并显示用户的IP地址。

3.8.3 802.1x 用户采用域配置的优先级顺序

优先级由高到低为：

1. 用户自带的域名

2. 系统视图下的默认域

3.8.4 MAC 旁路认证功能能否在主控板的固定接口上进行配置

不能。这个功能只在接口板上才支持。

4 终端接入配置

- 4.1 终端接入简介
- 4.2 终端接入配置注意事项
- 4.3 配置终端接入
- 4.4 终端接入配置举例

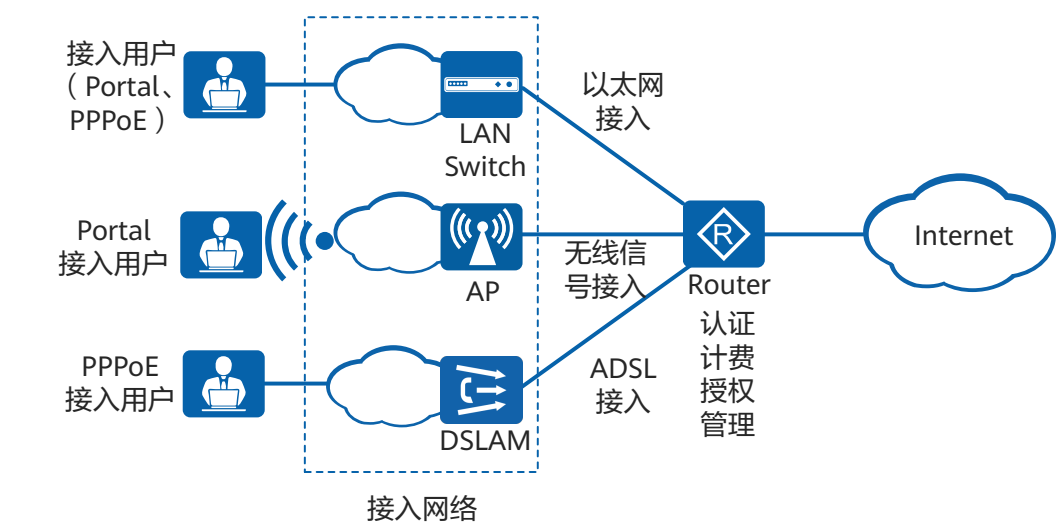
4.1 终端接入简介

背景信息

终端接入网关功能，支持PPPoE、IPoE、L2TP等终端用户的接入认证简单管理，作为小型企业100~500人左右的终端设备接入网管路由器，支持终端地址分配、终端用户认证等场景。

如图4-1所示，在宽带网络中，Router作为企业出口网关，同时作为终端接入设备，可以为各种宽带接入方式的用户，如为基于以太网接入LAN Switch、基于无线信号WLAN（Wireless Local Area Network）接入AP（Access Point）、基于ADSL（Asymmetric Digital Subscriber Line）接入DSLAM（Digital Subscriber Line Access Multiplexer）的用户提供基本的接入手段和宽带接入网的管理功能，实现用户的宽带上网等应用。

图 4-1 用户通过不同的宽带接入方式接入 Router



4.2 终端接入配置注意事项

涉及网元

表 4-1 本特性涉及网元

角色	产品	说明
AAA服务器	华为公司或第三方公司的AAA服务器产品。	负责对用户进行认证、计费和授权。
Portal服务器	华为公司或第三方公司的Portal服务器产品。	负责接收Portal客户端认证请求的服务器端系统，提供免费门户服务和基于Web认证的界面，与接入设备交互认证客户端的认证信息。 仅外置Portal认证方式需要该网元。

License 支持

终端接入是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

4.3 配置终端接入

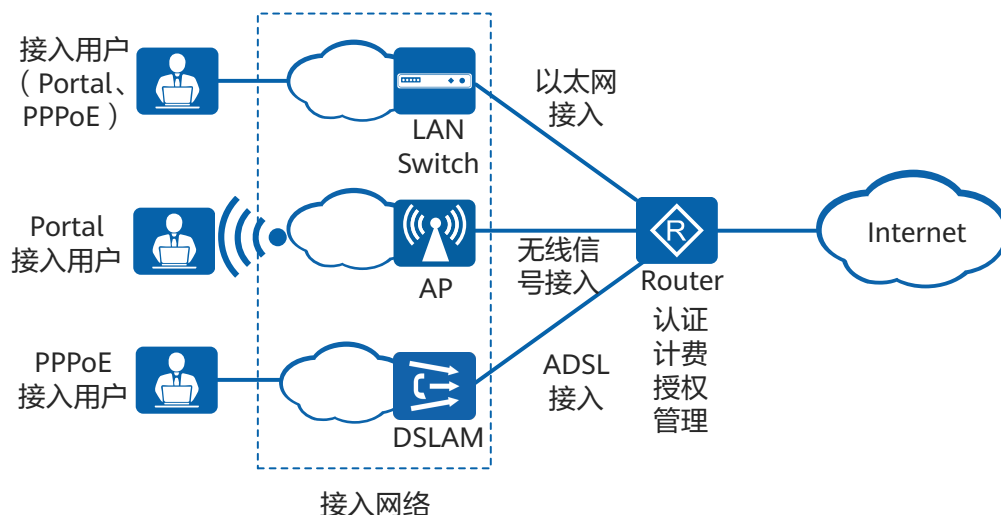
接入用户的认证

通过认证用来验证用户是否可以获得访问权，确定哪些用户可以访问网络。

如图4-2所示，用户物理接入方式的差异在接入设备上被屏蔽，Router可见的是用户报文的封装格式，即终端接入通过用户报文的协议栈来区分用户，对应不同的用户，灵活地选择不同的认证方式。

终端接入支持PPPoE认证和Portal认证两种认证方式。

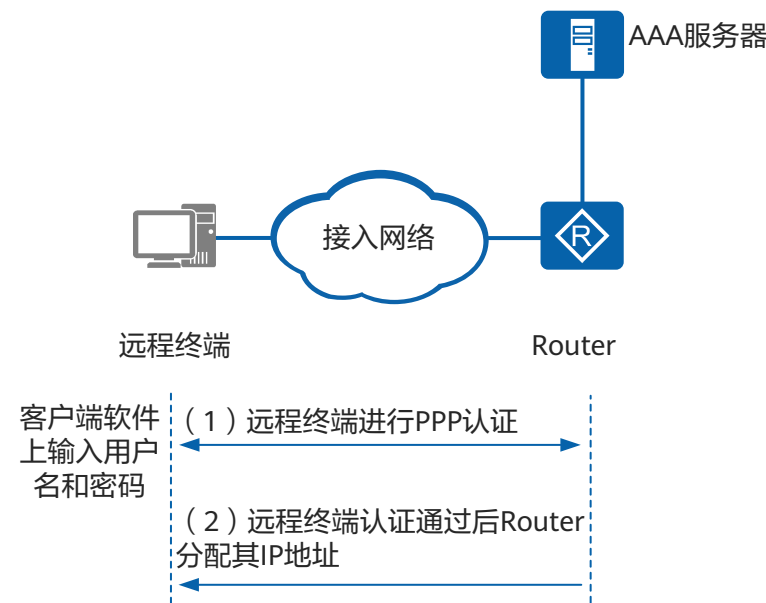
图 4-2 用户通过不同的宽带接入方式接入 Router



- PPPoE认证

如图4-3所示，PPPoE用户通过PPPoE拨号接入Internet（基于以太网和基于ADSL方式）。当PPPoE用户通过终端上的客户端软件进行PPPoE拨号，Router作为PPPoE Server对PPPoE用户进行PPP认证，用户的用户名和密码等用户信息在AAA服务器上完成认证。PPPoE用户认证通过后Router为其动态分配IP地址，使PPPoE用户可以访问Internet。

图 4-3 PPPoE 认证



有关Router作为PPPoE Server的配置，请参见《AR300, AR700 配置指南-广域网互联》中的“配置设备作为PPPoE Server”。

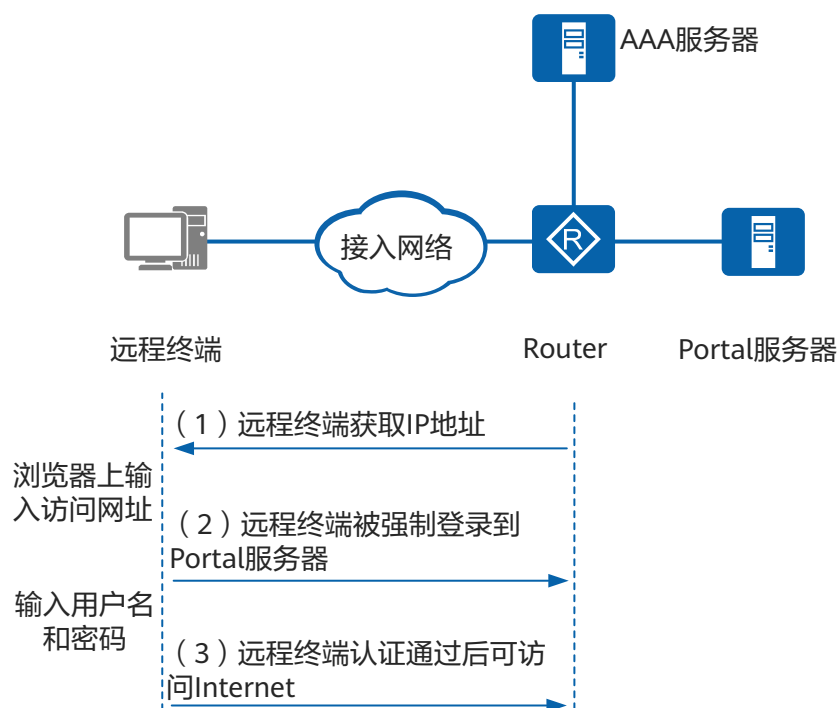
说明

除了通过使用全局地址池给PPPoE Client分配IP地址，设备还支持域下分配IP地址给接入用户，即在AAA业务方案中绑定IP地址池、域下绑定AAA业务方案，实现对应域下的用户上线后，设备分配其IP地址。域下分配IP地址优先级更高。

```
#
ip pool pool1
 gateway-list 192.168.1.1
 network 192.168.1.0 mask 255.255.255.0
#
aaa
 service-scheme sch1
  ip-pool pool1
  domain huawei
 service-scheme sch1
#
```

- Portal认证
- Portal认证，即Web认证：在用户未认证前试图访问其无权访问的地址时，Router将其访问请求强制重定向到Portal服务器，用户通过访问Portal服务器的认证页面，Router和远程终端交互信息后，用户的用户名和密码等用户信息在AAA服务器上完成认证。
- 如图4-4所示，Web用户通过访问Portal服务器的认证页面接入Internet（基于以太网和基于WLAN方式），Web用户先通过静态IP地址或DHCP获得IP地址后，上网过程中Web用户将被强制访问Portal认证网站，从而开始Portal认证过程。Web用户认证通过后，才可以访问Internet。

图 4-4 Portal 认证



有关Portal认证的配置，请参见《AR300, AR700 配置指南-安全配置》中的“[3.5 配置NAC](#)”。

说明

以上两种认证方式都需要结合AAA认证方案才能完成用户的身份认证，通过在Router上配置AAA，实现Router与AAA服务器的对接，由用户输入用户名和密码后，Router接收到用户的认证信息并将信息发送给AAA服务器，由AAA服务器对其进行认证。如果认证通过，则用户可以开始访问Internet。

在终端接入的配置中，可以选择本地方式或RADIUS方式的AAA认证方案。有关AAA认证方案的配置，请参见《AR300, AR700 配置指南-安全配置》中的“[1 AAA配置](#)”。

由于Router需要通过AAA服务器下发接入用户的带宽，所以需要了解Router支持的RADIUS属性。有关RADIUS属性的介绍，请参见《AR300, AR700 配置指南-安全配置》中的“[1.2.4.8 RADIUS属性](#)”。

PPPoE认证利用PPP协议的地址协商功能为用户分配IP地址，而Portal认证则需要预先为用户静态或动态配置IP地址。

- 有关静态IP地址的配置，请参见《AR300, AR700 配置指南-IP业务配置》中的“IP地址配置”。
- 有关DHCP方式获取IP地址的配置，请参见《AR300, AR700 配置指南-IP业务配置》中的“DHCP配置”。

接入用户的管理

接入用户上线后，Router通过AAA对接入用户进行管理，如对用户使用网络资源进行计费，控制在线用户的带宽，指定用户下线等。

- 基于域管理接入用户

AAA除了提供认证，还可以提供授权和计费这两种安全功能。AAA通过域来进行用户管理，用户的认证、授权、计费都需要在域下执行。所有对于接入用户的认证方案、授权方案、计费方案都是先在AAA视图下创建，再在域视图下引用对应的认证方案、授权方案、计费方案。

例如，同一域内的用户，可以访问相同的网址，享有相同的计费策略，以及享有相同的带宽策略。

说明

域下配置的授权信息较AAA服务器的授权信息优先级低，即优先使用AAA服务器下发的授权属性，在AAA服务器无该项授权或不支持该项授权时，域的授权属性生效。这样处理可以通过域管理进行灵活授权，而不必受限于AAA服务器提供的属性。

- 对接入用户的网络资源使用情况进行计费
 - Router通过RADIUS服务器基于流量或在线时长进行远端计费。
有关AAA计费方案的配置，请参见《AR300, AR700 配置指南-安全配置》中的“[1.8 配置采用RADIUS方式进行认证、授权和计费](#)”。
 - 基于目的地址计费DAA（Destination Address Accounting）
基于流量进行计费时，如果配置了DAA，用户可以免费访问特定的目的地址，如内网资源；当用户访问外部网络时，Router才按照访问流量进行计费。
有关DAA的配置，请参见《AR300, AR700 配置指南-安全配置》中的“[2.7 配置DAA](#)”。
- 控制接入用户的带宽
 - 选择本地方式的AAA认证方案时
需要在Router上创建QoS模板限定用户的上下行流量，并在AAA业务方案中引用QoS模板，实现不同域下接入用户的带宽不同。
 - i. 创建QoS模板，限定用户的上下行流量。

```
<Huawei> system-view
[Huawei] qos-profile profile1
[Huawei-qos-profile-profile1] car cir 200 pir 300 cbs 1500 pbs 3500 outbound
[Huawei-qos-profile-profile1] car cir 200 pir 300 cbs 1500 pbs 3500 inbound
[Huawei-qos-profile-profile1] quit
```
 - ii. 创建AAA业务方案，引用QoS模板。

```
[Huawei] aaa
[Huawei-aaa] service-scheme scheme1
[Huawei-aaa-service-scheme1] qos-profile profile1
[Huawei-aaa-service-scheme1] quit
```
 - iii. 创建AAA域，引用AAA业务方案。

```
[Huawei-aaa] domain huawei
[Huawei-aaa-domain-huawei] service-scheme scheme1
```
 - 选择RADIUS方式的AAA认证方案时
AAA服务器下发对应域的带宽，不同域下接入用户的带宽不同。

4.4 终端接入配置举例

4.4.1 配置 Portal 认证的终端接入示例

组网需求

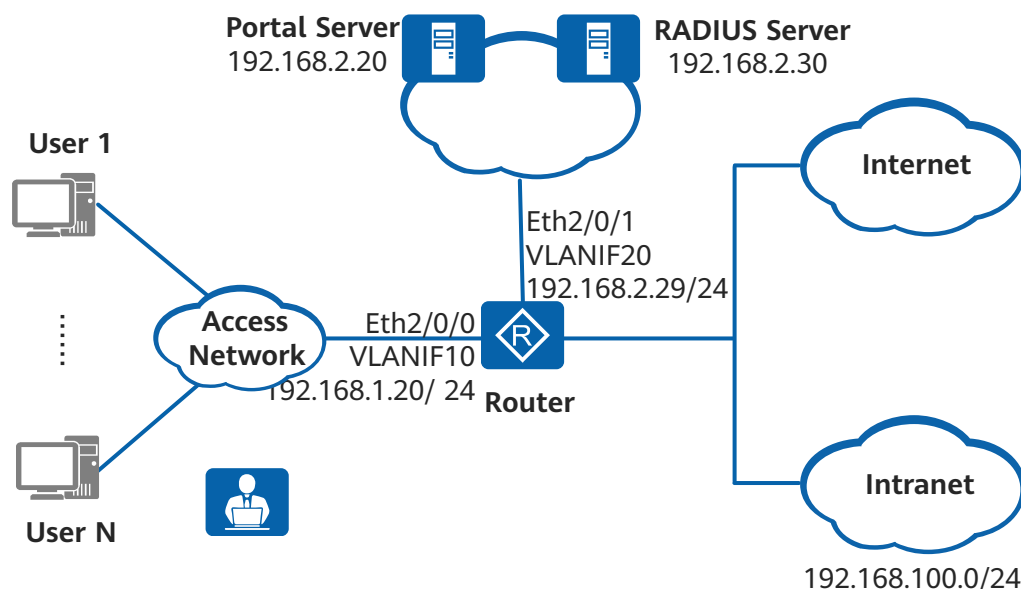
如[图4-5](#)所示，某企业终端用户通过Router（出口网关兼接入设备）接入Internet。Router需对用户进行认证计费及用户管理功能。

企业希望：

- 对终端用户采用Portal认证方式。终端用户只有通过认证后，Router才允许其访问Internet。

- 终端用户接入成功后，访问企业内部（192.168.100.0/24）流量时Router不对其进行计费，访问外网流量时Router按时长计费。
- 如果发现某上线用户为非法用户，可通过指定终端用户的IP地址，强制其下线。

图 4-5 配置 Portal 认证的终端接入组网图



配置思路

在Router上完成以下配置：

1. 配置采用RADIUS方式的AAA认证和计费方案，保证Router与RADIUS服务器之间的信息交互。
2. 配置Portal认证功能，对接入用户进行Portal认证。
3. 配置DAA，实现对接入成功终端用户访问企业内部（192.168.100.0/24）流量时Router不对其进行计费，访问外网流量时Router按时长计费。
4. 发现IP地址为192.168.1.3/24的接入用户为非法用户，Router强制其下线。

操作步骤

步骤1 创建VLAN并配置接口允许通过的VLAN，保证网络通畅。

创建VLAN 10和VLAN 20。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20
```

配置Router与用户连接的接口为trunk类型接口，并将该接口加入VLAN 10。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type trunk
[Router-Ethernet2/0/0] undo port trunk allow-pass vlan 1
[Router-Ethernet2/0/0] port trunk allow-pass vlan 10
[Router-Ethernet2/0/0] quit
```

配置Router连接RADIUS服务器的接口为trunk类型接口，并将该接口加入VLAN 20。


```
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type trunk
[Router-Ethernet2/0/1] undo port trunk allow-pass vlan 1
[Router-Ethernet2/0/1] port trunk allow-pass vlan 20
[Router-Ethernet2/0/1] quit
```

创建VLANIF 10和VLANIF 20，并配置VLANIF的IP地址，以使用户终端、Router、企业内网资源之间能够建立起路由。

```
[Router] interface vlanif 10
[Router-Vlanif10] ip address 192.168.1.20 24
[Router-Vlanif10] quit
[Router] interface vlanif 20
[Router-Vlanif20] ip address 192.168.2.29 24
[Router-Vlanif20] quit
```

步骤2 创建并配置RADIUS服务器模板、AAA认证方案和计费方案以及认证域。

说明

请确保RADIUS服务器模板内的共享密钥和RADIUS服务器上的配置保持一致。

创建并配置RADIUS服务器模板rd1。

```
[Router] radius-server template rd1
[Router-radius-rd1] radius-server authentication 192.168.2.30 1812
[Router-radius-rd1] radius-server accounting 192.168.2.30 1813
[Router-radius-rd1] radius-server shared-key cipher YsHsjx_202206
[Router-radius-rd1] quit
```

创建AAA方案并配置认证方案auth，认证模式为RADIUS认证。

```
[Router] aaa
[Router-aaa] authentication-scheme auth
[Router-aaa-authen-auth] authentication-mode radius
[Router-aaa-authen-auth] quit
```

在AAA方案中配置计费方案abc，计费模式为RADIUS计费。

```
[Router-aaa] accounting-scheme abc
[Router-aaa-accounting-abc] accounting-mode radius
[Router-aaa-accounting-abc] quit
```

配置AAA域isp1，在域下应用认证方案auth、计费方案abc和RADIUS服务器模板rd1。

```
[Router-aaa] domain isp1
[Router-aaa-domain-isp1] authentication-scheme auth
[Router-aaa-domain-isp1] accounting-scheme abc
[Router-aaa-domain-isp1] radius-server rd1
[Router-aaa-domain-isp1] quit
[Router-aaa] quit
```

配置全局默认域为isp1。用户进行接入认证时，以格式“user@isp1”输入用户名即可在isp1域下进行aaa认证。如果用户名中不携带域名或携带的域名不存在，用户将会在默认域中进行认证。

```
[Router] domain isp1
```

步骤3 配置Portal认证。

创建并配置名称为abc的Portal服务器模板。

```
[Router] web-auth-server abc
[Router-web-auth-server-abc] server-ip 192.168.2.20
[Router-web-auth-server-abc] port 50200
[Router-web-auth-server-abc] url http://192.168.2.20:8080/webagent
```

配置设备与Portal服务器信息交互的共享密钥为YsHsjx_202206，并以密文形式显示。

```
[Router-web-auth-server-abc] shared-key cipher YsHsjx_202206
```

配置Portal认证探测与逃生功能。

```
[Router-web-auth-server-abc] server-detect action log
[Router-web-auth-server-abc] user-sync
[Router-web-auth-server-abc] quit
```

说明

如果Portal服务器不支持探测，则无需配置该功能。

执行命令**user-sync**时，请务必确保Portal服务器支持该功能，否则会导致用户下线。

配置Portal接入模板“web1”。

```
[Router] portal-access-profile name web1
[Router-portal-access-profile-web1] web-auth-server abc direct
[Router-portal-access-profile-web1] quit
```

配置认证模板“p1”，并在其上绑定Portal接入模板“web1”。

```
[Router] authentication-profile name p1
[Router-authen-profile-p1] portal-access-profile web1
[Router-authen-profile-p1] quit
```

在接口VLANIF10上绑定认证模板“p1”，使能Portal认证。

```
[Router] interface vlanif 10
[Router-Vlanif10] authentication-profile p1
[Router-Vlanif10] quit
```

步骤4 配置DAA。

配置流量的识别规则ACL3000，对用户访问内网的流量进行识别，假设内网网段为192.168.100.0/24。

```
[Router] acl 3000
[Router-acl-adv-3000] rule 5 permit ip destination 192.168.100.0 0.0.0.255
[Router-acl-adv-3000] quit
```

配置访问内网流量的费率级别为1。

```
[Router] traffic-group huawei
[Router-traffic-group-huawei] acl 3000 tariff-level 1
[Router-traffic-group-huawei] quit
[Router] traffic-group huawei enable
```

配置对除了匹配ACL 3000的所有流量进行计费。

- 对于费率级别1的流量，不统计流量同时不计费。
- 对于其他流量，设备将流量信息进行统计后发送给RADIUS计费服务器。

```
[Router] aaa
[Router-aaa] domain isp1
[Router-aaa-domain-isp1] statistic enable
[Router-aaa-domain-isp1] quit
```

步骤5 强制IP地址为192.168.1.3的接入用户下线。

```
[Router-aaa] cut access-user ip-address 192.168.1.3
[Router-aaa] quit
[Router] quit
```

步骤6 验证配置结果。

执行命令**display web-auth-server configuration**查看Portal服务器相关的配置信息。

```
<Router> display web-auth-server configuration
Listening port      : 2000
Portal              : version 1, version 2
Include reply message : enabled

-----

Web-auth-server Name : abc
IP-address           : 192.168.2.20
Shared-key           : %^%#s@<60z+%""EJl#4KOij5M)"m&9%"k:63Vl+xTc"K%^%#
Source-IP            : -
Port / PortFlag      : 50200 / NO
URL                  : http://192.168.2.20:8080/webagent
URL Template         :
Redirection          : Enable
Sync                 : Enable
Sync Seconds         : 300
Sync Max-times       : 3
Detect               : Enable
Detect Seconds       : 60
Detect Max-times     : 3
Detect Critical-num  : 0
Detect Action        : log
Bound Vlanif         : 10
VPN Instance         :
Bound Interface      :

-----

1 Web authentication server(s) in total
```

执行命令**display traffic-group name**，查看流量组huawei中的信息。

```
<Router> display traffic-group name huawei

-----
Acl-id      Tariff-level
-----
3000        1
-----
Total: 1
```

当用户成功上线后，可以通过**display access-user**命令查看流量统计信息。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10 20
#
authentication-profile name p1
portal-access-profile web1

#
domain isp1
#
radius-server template rd1
radius-server shared-key cipher %^%#s@<60z+%""EJl#4KOij5M)"m&9%"k:63Vl+xTc"K%^%#
radius-server authentication 192.168.2.30 1812 weight 80
radius-server accounting 192.168.2.30 1813 weight 80
#
acl number 3000
rule 5 permit ip destination 192.168.100.0 0.0.0.255
#
web-auth-server abc
```

```
server-ip 192.168.2.20
port 50200
shared-key cipher %^%#s@<60z+%""EJl#4KOij5M)"m&9%"k:63Vl+xTc"K%^%#
url http://192.168.2.20:8080/webagent
server-detect action log
user-sync
#
portal-access-profile name web1
web-auth-server abc direct

#
aaa
authentication-scheme auth
authentication-mode radius
accounting-scheme abc
accounting-mode radius
domain isp1
authentication-scheme auth
accounting-scheme abc
radius-server rd1
statistic enable
#
interface Vlanif10
ip address 192.168.1.20 255.255.255.0
authentication-profile p1
#
interface Vlanif20
ip address 192.168.2.29 255.255.255.0
#
interface Ethernet2/0/0
port link-type trunk
undo port trunk allow-pass vlan 1
port trunk allow-pass vlan 10
#
interface Ethernet2/0/1
port link-type trunk
undo port trunk allow-pass vlan 1
port trunk allow-pass vlan 20
#
traffic-group huawei
acl 3000 tariff-level 1
traffic-group huawei enable
#
return
```

4.4.2 配置 PPPoE 认证的终端接入示例

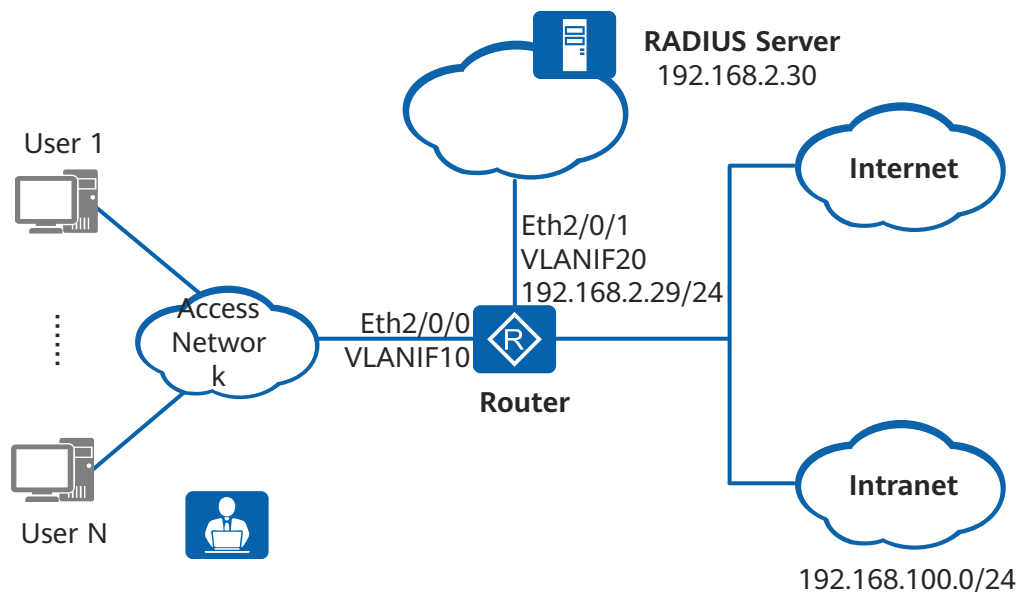
组网需求

如图4-6所示，某企业终端用户通过Router（出口网关兼接入设备）接入Internet。Router需对用户进行认证计费及用户管理功能。

企业希望：

- 对终端用户采用PPPoE认证方式。终端用户只有通过认证后，Router才允许其访问Internet。
- 终端用户接入成功后，访问企业内部（192.168.100.0/24）流量时Router不对其进行计费，访问其他外网流量时Router按时长计费。
- 如果发现某上线用户为非法用户，可通过指定终端用户的IP地址，强制其下线。

图 4-6 配置 PPPoE 认证的终端接入组网图



配置思路

在Router上完成以下配置：

1. 配置采用RADIUS方式的AAA认证和计费方案，保证Router与RADIUS服务器之间的信息交互。
2. 配置PPPoE Server功能，对接入用户进行PPP认证。
3. 配置DAA，实现对接入成功终端用户访问企业内部流量时Router不对其进行计费，访问其他外网流量时Router按时长计费。
4. 发现IP地址为192.168.1.3/24的接入用户为非法用户，Router强制其下线。

操作步骤

步骤1 创建VLAN并配置接口允许通过的VLAN，保证网络通畅。

创建VLAN 10和VLAN 20。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20
```

配置Router与用户连接的接口为trunk类型接口，并将该接口加入VLAN 10。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type trunk
[Router-Ethernet2/0/0] undo port trunk allow-pass vlan 1
[Router-Ethernet2/0/0] port trunk allow-pass vlan 10
[Router-Ethernet2/0/0] quit
```

配置Router连接RADIUS服务器的接口为trunk类型接口，并将该接口加入VLAN 20。

```
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type trunk
[Router-Ethernet2/0/1] undo port trunk allow-pass vlan 1
[Router-Ethernet2/0/1] port trunk allow-pass vlan 20
[Router-Ethernet2/0/1] quit
```

创建VLANIF 10和VLANIF 20，并配置VLANIF 20的IP地址，以使用户终端、Router、企业内网资源之间能够建立起路由。

```
[Router] interface vlanif 10
[Router-Vlanif10] quit
[Router] interface vlanif 20
[Router-Vlanif20] ip address 192.168.2.29 24
[Router-Vlanif20] quit
```

步骤2 创建并配置RADIUS服务器模板、AAA认证方案、计费方案以及认证域。

说明

请确保RADIUS服务器模板内的共享密钥和RADIUS服务器上的配置保持一致。

创建并配置RADIUS服务器模板rd1。

```
[Router] radius-server template rd1
[Router-radius-rd1] radius-server authentication 192.168.2.30 1812
[Router-radius-rd1] radius-server accounting 192.168.2.30 1813
[Router-radius-rd1] radius-server shared-key cipher YsHsjx_202206
[Router-radius-rd1] quit
```

创建AAA方案并配置认证方案auth，认证模式为RADIUS认证。

```
[Router] aaa
[Router-aaa] authentication-scheme auth
[Router-aaa-authen-auth] authentication-mode radius
[Router-aaa-authen-auth] quit
```

在AAA方案中配置计费方案abc，计费模式为RADIUS计费。

```
[Router-aaa] accounting-scheme abc
[Router-aaa-accounting-abc] accounting-mode radius
[Router-aaa-accounting-abc] quit
```

配置AAA域isp1，在域下应用认证方案auth、计费方案abc和RADIUS服务器模板rd1。

```
[Router-aaa] domain isp1
[Router-aaa-domain-isp1] authentication-scheme auth
[Router-aaa-domain-isp1] accounting-scheme abc
[Router-aaa-domain-isp1] radius-server rd1
[Router-aaa-domain-isp1] quit
[Router-aaa] quit
```

配置全局默认域为isp1。用户进行接入认证时，以格式“user@isp1”输入用户名即可在isp1域下进行aaa认证。如果用户名中不携带域名或携带的域名不存在，用户将会在默认域中进行认证。

```
[Router] domain isp1
```

步骤3 配置PPPoE Server。

配置全局地址池，实现PPPoE Server为接入用户动态分配IP地址。

```
[Router] ip pool pool1
[Router-ip-pool-pool1] network 192.168.1.0 mask 255.255.255.0
[Router-ip-pool-pool1] gateway-list 192.168.1.1
[Router-ip-pool-pool1] quit
```

创建并配置虚拟接口模板。

```
[Router] interface virtual-template 1
[Router-Virtual-Template1] ppp authentication-mode chap domain isp1
[Router-Virtual-Template1] ip address 192.168.1.1 255.255.255.0
[Router-Virtual-Template1] remote address pool pool1
[Router-Virtual-Template1] quit
```

在VLANIF10接口上启用PPPoE协议。

```
[Router] interface vlanif10
[Router-Vlanif10] pppoe-server bind virtual-template 1
[Router-Vlanif10] quit
```

步骤4 配置DAA。

配置流量的识别规则ACL3000，对用户访问内网的流量进行识别，假设内网网段为192.168.100.0/24。

```
[Router] acl 3000
[Router-acl-adv-3000] rule 5 permit ip destination 192.168.100.0 0.0.0.255
[Router-acl-adv-3000] quit
```

配置访问内网流量的费率级别为1。

```
[Router] traffic-group huawei
[Router-traffic-group-huawei] acl 3000 tariff-level 1
[Router-traffic-group-huawei] quit
[Router] traffic-group huawei enable
```

配置对除了匹配ACL 3000的所有流量进行计费。

- 对于费率级别1的流量，不统计流量同时不计费。
- 对于其他流量，设备将流量信息进行统计后发送给RADIUS计费服务器。

```
[Router] aaa
[Router-aaa] domain isp1
[Router-aaa-domain-isp1] statistic enable
[Router-aaa-domain-isp1] quit
```

步骤5 强制IP地址为192.168.1.3的接入用户下线。

```
[Router-aaa] cut access-user ip-address 192.168.1.3
[Router-aaa] quit
[Router] quit
```

步骤6 验证配置结果。

执行命令**display pppoe-server session all**，查看PPPoE会话的状态信息和配置信息。根据显示信息判断会话状态是否正常（状态为Up表示正常）、配置是否正确（是否和之前的数据规划和组网一致）。

执行命令**display traffic-group name**，查看流量组huawei中的信息。

```
<Router> display traffic-group name huawei
```

Acl-id	Tariff-level
3000	1
Total: 1	

当用户成功上线后，可以通过**display access-user**命令查看上线用户的IP地址和流量统计信息。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10 20
```

```
#
domain isp1
#
radius-server template rd1
radius-server shared-key cipher %%%s@<60z+%""EJl#4KOij5M)"m&9%"k:63Vl+xTc"K%###
radius-server authentication 192.168.2.30 1812 weight 80
radius-server accounting 192.168.2.30 1813 weight 80
#
acl number 3000
rule 5 permit ip destination 192.168.100.0 0.0.0.255
#
ip pool pool1
gateway-list 192.168.1.1
network 192.168.1.0 mask 255.255.255.0
#
aaa
authentication-scheme auth
authentication-mode radius
accounting-scheme abc
accounting-mode radius
domain isp1
authentication-scheme auth
accounting-scheme abc
radius-server rd1
statistic enable
#
interface Vlanif10
pppoe-server bind Virtual-Template 1
#
interface Vlanif20
ip address 192.168.2.29 255.255.255.0
#
interface Ethernet2/0/0
port link-type trunk
undo port trunk allow-pass vlan 1
port trunk allow-pass vlan 10
#
interface Ethernet2/0/1
port link-type trunk
undo port trunk allow-pass vlan 1
port trunk allow-pass vlan 20
#
interface Virtual-Template1
ppp authentication-mode chap domain isp1
remote address pool pool1
ip address 192.168.1.1 255.255.255.0
#
traffic-group huawei
acl 3000 tariff-level 1
traffic-group huawei enable
#
return
```


5 ACL 配置

设备为了对不同类的报文进行不同的处理，需要配置一系列的规则，以对报文进行分类，这些规则就是通过访问控制列表ACL定义的。

5.1 ACL简介

介绍ACL的定义和作用。

5.2 ACL原理描述

介绍ACL的实现原理。

5.3 ACL应用场景

介绍ACL的应用场景。

5.4 ACL配置任务概览

设备支持的ACL主要包括：基本ACL、高级ACL、二层ACL、用户ACL、基本ACL6和高级ACL6。

5.5 ACL配置注意事项

介绍ACL的配置注意事项。

5.6 ACL缺省配置

介绍ACL缺省配置，实际应用的配置可以基于缺省配置进行修改。

5.7 配置ACL

介绍ACL详细的配置过程。

5.8 维护ACL

介绍如何维护ACL。

5.9 ACL配置举例

5.10 ACL常见配置错误

5.11 ACL FAQ

介绍配置过程中常见的问题，以及解决方法。

5.1 ACL 简介

介绍ACL的定义和作用。

定义

访问控制列表ACL（Access Control List）是由一条或多条规则组成的集合。所谓规则，是指描述报文匹配条件的判断语句，这些条件可以是报文的源地址、目的地址、端口号等。

ACL本质上是一种报文过滤器，规则是过滤器的滤芯。设备基于这些规则进行报文匹配，可以过滤出特定的报文，并根据应用ACL的业务模块的处理策略来允许或阻止该报文通过。

说明

配置ACL后，还需将ACL在业务模块中应用，ACL才能生效。

ACL可以应用于诸多业务模块，其中最基本的ACL应用，就是在简化流策略/流策略中应用ACL，使设备能够基于全局、VLAN或接口下发ACL，实现对转发报文的过滤。此外，ACL还可以应用在Telnet、FTP、路由等模块。业务模块之间的ACL默认处理动作和处理机制有所不同，具体请参见[5.2.7 ACL应用模块的ACL默认动作和处理机制](#)。

目的

随着网络的飞速发展，网络安全和网络服务质量QoS（Quality of Service）问题日益突出。

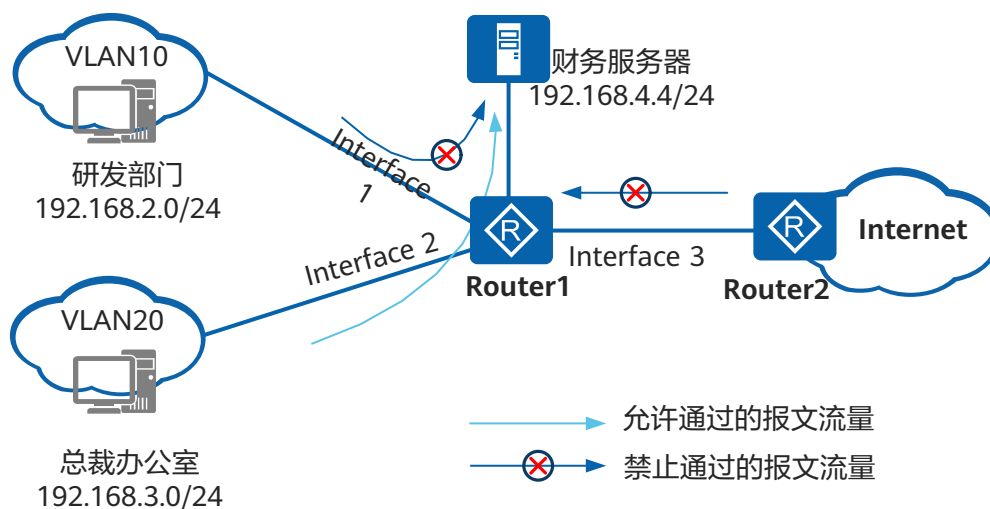
- 企业重要服务器资源被随意访问，企业机密信息容易泄露，造成安全隐患。
- Internet病毒肆意侵略企业内网，内网环境的安全性堪忧。
- 网络带宽被各类业务随意挤占，服务质量要求最高的语音、视频业务的带宽得不到保障，造成用户体验差。

以上种种问题，都对正常的网络通信造成了很大的影响。因此，提高网络安全性服务质量迫在眉睫。ACL就在这种情况下应运而生了。

通过ACL可以实现对网络中报文流的精确识别和控制，达到控制网络访问行为、防止网络攻击和提高网络带宽利用率的目的，从而切实保障网络环境的安全性和网络服务质量的可靠性。

图5-1是一个典型的ACL应用组网场景。

图 5-1 ACL 典型应用场景



- 某企业为保证财务数据安全，禁止研发部门访问财务服务器，但总裁办公室不受限制。实现方式：
在Interface 1的入方向上部署ACL，禁止研发部门访问财务服务器的报文通过。Interface 2上无需部署ACL，总裁办公室访问财务服务器的报文默认允许通过。
- 保护企业内网环境安全，防止Internet病毒入侵。实现方式：
在Interface 3的入方向上部署ACL，将病毒经常使用的端口予以封堵。

5.2 ACL 原理描述

介绍ACL的实现原理。

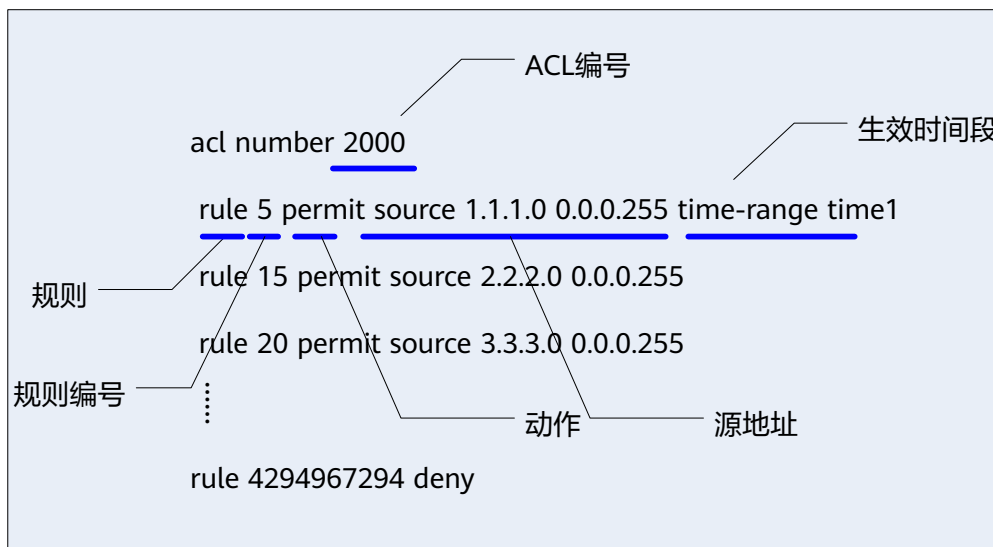
5.2.1 ACL 的基本原理

ACL由一系列规则组成，通过将报文与ACL规则进行匹配，设备可以过滤出特定的报文。

ACL 的组成

一条ACL的结构组成，如图5-2所示。

图 5-2 ACL 的结构组成



- ACL编号**：用于标识ACL，表明该ACL是数字型ACL。
根据ACL规则功能的不同，ACL被划分为基本ACL、高级ACL、二层ACL和用户ACL这几种类型，每类ACL编号的取值范围不同。关于每类ACL编号的详细介绍，请参见[5.2.2 ACL的分类](#)。
除了可以通过ACL编号标识ACL，设备还支持通过名称来标识ACL，就像用域名代替IP地址一样，更加方便记忆。这种ACL，称为命名型ACL。
命名型ACL实际上是“名字+数字”的形式，可以在定义命名型ACL时同时指定ACL编号。如果不指定编号，则由系统自动分配。例如，下面就是一个既有名字“deny-telnet-login”又有编号“3998”的ACL。

```
#
acl name deny-telnet-login 3998
rule 0 deny tcp source 10.152.0.0 0.0.63.255 destination 10.64.0.97 0 destination-port eq
telnet
rule 5 deny tcp source 10.242.128.0 0.0.127.255 destination 10.64.0.97 0 destination-port eq
telnet
#
```

- **规则：**即描述报文匹配条件的判断语句。
 - **规则编号：**用于标识ACL规则。可以自行配置规则编号，也可以由系统自动分配。

ACL规则的编号范围是0～4294967294，所有规则均按照规则编号从小到大进行排序。所以，图5-2中的rule 5排在首位，而规则编号最大的rule 4294967294排在末位。系统按照规则编号从小到大的顺序，将规则依次与报文匹配，一旦匹配上一条规则即停止匹配。
 - **动作：**包括permit/deny两种动作，表示允许/拒绝。
 - **匹配项：**ACL定义了极其丰富的匹配项。除了图5-2中的源地址和生效时间段，ACL还支持很多其他规则匹配项。例如，二层以太网帧头信息（如源MAC、目的MAC、以太帧协议类型）、三层报文信息（如目的地址、协议类型）以及四层报文信息（如TCP/UDP端口号）等。关于每种匹配项的详细介绍，请参见5.2.5 ACL的常用匹配项。

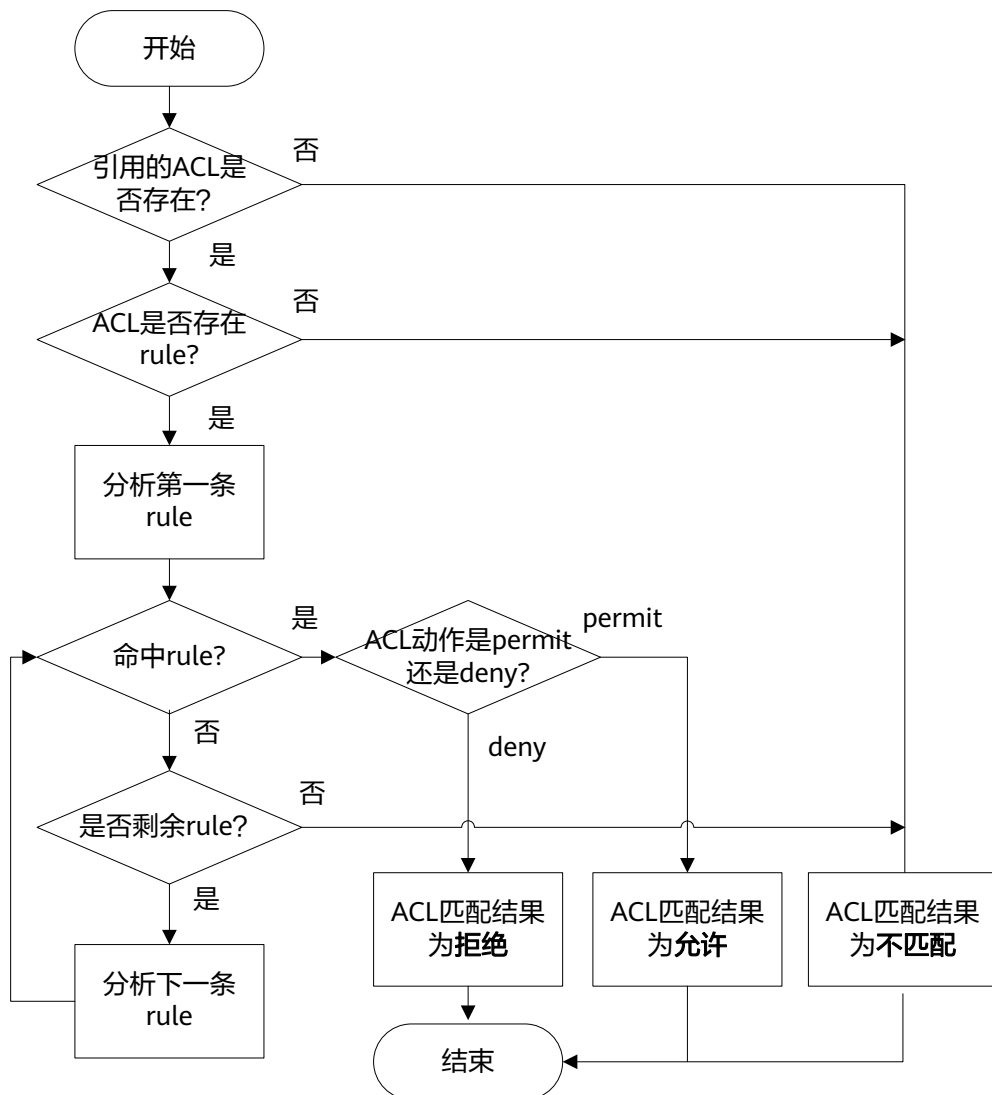
说明

如果设备启动使用的配置文件中配置了超规格的ACL规则，当设备启动加载该配置文件时，能生成ACL配置，但有部分配置不生效。

ACL 的匹配机制

设备将报文与ACL规则进行匹配时，遵循“一旦命中即停止匹配”的机制，如图5-3所示。

图 5-3 ACL 的匹配机制



首先系统会查找设备上是否配置了ACL。

- 如果ACL不存在，则返回ACL匹配结果为：不匹配。
- 如果ACL存在，则查找设备是否配置了ACL规则。
 - 如果规则不存在，则返回ACL匹配结果为：不匹配。
 - 如果规则存在，则系统会从ACL中编号最小的规则开始查找。
 - 如果匹配上了permit规则，则停止查找规则，并返回ACL匹配结果为：匹配（允许）。
 - 如果匹配上了deny规则，则停止查找规则，并返回ACL匹配结果为：匹配（拒绝）。
 - 如果未匹配上规则，则继续查找下一条规则，以此循环。如果一直查到最后一条规则，报文仍未匹配上，则返回ACL匹配结果为：不匹配。

从整个ACL匹配流程可以看出，报文与ACL规则匹配后，会产生两种匹配结果：“匹配”和“不匹配”。

- 匹配（命中规则）：指存在ACL，且在ACL中查找到了符合匹配条件的规则。
不论匹配的动作是“permit”还是“deny”，都称为“匹配”，而不是只是匹配上permit规则才算“匹配”。
- 不匹配（未命中规则）：指不存在ACL，或ACL中无规则，再或者在ACL中遍历了所有规则都没有找到符合匹配条件的规则。
以上三种情况，都叫做“不匹配”。

说明

无论报文匹配ACL的结果是“不匹配”、“允许”还是“拒绝”，该报文最终是被允许通过还是拒绝通过，实际是由应用ACL的各个业务模块来决定。不同的业务模块，对命中和未命中规则报文的处理方式也各不相同。例如，在Telnet模块中应用ACL，只要报文命中了permit规则，就允许通过；而在流策略中应用ACL，如果报文命中了permit规则，但流行为动作配置的是deny，该报文仍会被拒绝通过。关于各个业务模块ACL处理机制的详细介绍，请参见[5.2.7 ACL应用模块的ACL默认动作和处理机制](#)。

5.2.2 ACL 的分类

基于 ACL 标识方法的划分

划分如下：

- 数字型ACL：传统的ACL标识方法。创建ACL时，指定一个唯一的数字标识该ACL。
- 命名型ACL：通过名称代替编号来标识ACL。

用户在创建ACL时可以为该指定编号，不同的编号对应不同类型的ACL，如[表5-1](#)所示。同时，为了便于记忆和识别，用户还可以创建命名型ACL，即在创建ACL时为其设置名称。命名型ACL，也可以是“名称 数字”的形式，即在定义命名型ACL时，同时指定ACL编号。如果不指定编号，系统则会自动为其分配一个数字型ACL的编号。

说明

命名型ACL一旦创建成功，便不允许用户再修改其名称。如果删除ACL名称，则表示删除整个ACL。仅基本ACL与基本ACL6，以及高级ACL与高级ACL6，可以使用相同的ACL名称；其他类型ACL之间，不能使用相同的ACL名称。

基于对 IPv4 和 IPv6 支持情况的划分

划分如下：

- ACL4：通常直接叫做“ACL”，特指仅支持过滤IPv4报文的ACL。
- ACL6：又叫做“IPv6 ACL”，特指仅支持过滤IPv6报文的ACL。

以上两种ACL，以及既支持过滤IPv4报文又支持过滤IPv6报文的ACL，统一称做“ACL”。各类型ACL对IPv4和IPv6的支持情况，如[表5-1](#)所示。

基于 ACL 规则定义方式的划分

[表5-1](#)所示，基于ACL规则定义方式的划分如下。

表 5-1 基于 ACL 规则定义方式的 ACL 分类

分类	适用的IP版本	规则定义描述	编号范围
基本ACL	IPv4	仅使用报文的源IP地址、分片信息和生效时间段信息来定义规则。	2000 ~ 2999
高级ACL	IPv4	既可使用IPv4报文的源IP地址，也可使用目的IP地址、IP协议类型、ICMP类型、TCP源/目的端口、UDP源/目的端口号、生效时间段等来定义规则。	3000 ~ 3999
二层ACL	IPv4&IPv6	使用报文的以太网帧头信息来定义规则，如根据源MAC（Media Access Control）地址、目的MAC地址、二层协议类型等。	4000 ~ 4999
用户ACL	IPv4	既可使用IPv4报文的源IP地址，也可使用目的IP地址、IP协议类型、ICMP类型、TCP源端口/目的端口、UDP源端口/目的端口号等来定义规则。	6000 ~ 6031
基本ACL6	IPv6	可使用IPv6报文的源IPv6地址、分片信息和生效时间段来定义规则。	2000 ~ 2999
高级ACL6	IPv6	可以使用IPv6报文的源IPv6地址、目的IPv6地址、IPv6协议类型、ICMPv6类型、TCP源/目的端口、UDP源/目的端口号、生效时间段等来定义规则。	3000 ~ 3999

5.2.3 ACL 的步长设定

步长的含义

步长，是指系统自动为ACL规则分配编号时，每个相邻规则编号之间的差值。

系统为ACL中首条未手工指定编号的规则分配编号时，使用步长值作为该规则的起始编号；为后续规则分配编号时，则使用大于当前ACL内最大规则编号且是步长整数倍的最小整数作为规则编号。例如ACL中包含规则rule 5和rule 12，ACL（特指ACL4）的缺省步长为5，大于12且是5的倍数的最小整数是15，所以系统分配给新配置的规则的编号为15。

```
[Huawei-acl-basic-2001] display this
#
acl number 2001          //空ACL
#
return
[Huawei-acl-basic-2001] rule deny source 10.1.1.0 0.0.0.255 //配置首条不指定规则编号的规则
[Huawei-acl-basic-2001] display this
#
```

```
acl number 2001
 rule 5 deny source 10.1.1.0 0.0.0.255
#
return
[Huawei-acl-basic-2001] rule 12 deny source 10.2.2.0 0.0.0.255 //配置一条规则编号为12的规则
[Huawei-acl-basic-2001] display this
#
acl number 2001
 rule 5 deny source 10.1.1.0 0.0.0.255
 rule 12 deny source 10.2.2.0 0.0.0.255
#
return
[Huawei-acl-basic-2001] rule deny source 10.3.3.0 0.0.0.255 //再次配置一条不指定规则编号的规则
[Huawei-acl-basic-2001] display this
#
acl number 2001
 rule 5 deny source 10.1.1.0 0.0.0.255
 rule 12 deny source 10.2.2.0 0.0.0.255
 rule 15 deny source 10.3.3.0 0.0.0.255
#
return
```

如果重新调整了步长值（例如调整为2），系统则会自动从当前步长值开始重新排列规则编号，规则编号变成2、4、6…。恢复步长值为缺省值后，系统则会立刻按照缺省步长重新调整规则编号，规则编号变成5、10、15…。

```
[Huawei-acl-basic-2001] display acl 2001
Basic ACL 2001, 3 rules
Acl's step is 5
 rule 5 deny source 10.1.1.0 0.0.0.255
 rule 12 deny source 10.2.2.0 0.0.0.255
 rule 15 deny source 10.3.3.0 0.0.0.255

[Huawei-acl-basic-2001] step 2 //配置步长值为2
[Huawei-acl-basic-2001] display acl 2001
Basic ACL 2001, 3 rules
Acl's step is 2
 rule 2 deny source 10.1.1.0 0.0.0.255
 rule 4 deny source 10.2.2.0 0.0.0.255
 rule 6 deny source 10.3.3.0 0.0.0.255

[Huawei-acl-basic-2001] undo step //恢复步长值为缺省值
[Huawei-acl-basic-2001] display acl 2001
Basic ACL 2001, 3 rules
Acl's step is 5
 rule 5 deny source 10.1.1.0 0.0.0.255
 rule 10 deny source 10.2.2.0 0.0.0.255
 rule 15 deny source 10.3.3.0 0.0.0.255
```

步长的作用

设置步长的作用，在于方便后续在旧规则之间插入新的规则。

假设，一条ACL中，已包含了三条规则rule 5、rule 10、rule 15。如果希望源IP地址为10.1.1.3的报文也被拒绝通过，该如何处理？

```
rule 5 deny source 10.1.1.1 0 //表示拒绝源IP地址为10.1.1.1的报文通过
rule 10 deny source 10.1.1.2 0 //表示拒绝源IP地址为10.1.1.2的报文通过
rule 15 permit source 10.1.1.0 0.0.0.255 //表示允许源IP地址为10.1.1.0/24网段地址的报文通过
```

由于ACL匹配报文时遵循“一旦命中即停止匹配”的原则，所以源IP地址为10.1.1.1和10.1.1.2的报文，会在匹配上编号较小的rule 5和rule 10后停止匹配，从而被系统拒绝通过；而源IP地址为10.1.1.3的报文，则只会命中rule 15，从而得到系统允许通过。若想让源IP地址为10.1.1.3的报文也被拒绝通过，则必须为该报文配置一条新的deny规则。可以在rule 15之前插入一条新规则rule 11，这样源IP地址为10.1.1.3的报文，就会

因先命中rule 11而被系统拒绝通过。插入rule 11后，该ACL的旧规则编号不受影响，且新的规则排序为rule 5、rule 10、rule 11、rule 15。

```
rule 5 deny source 10.1.1.1 0 //表示禁止源IP地址为10.1.1.1的报文通过
rule 10 deny source 10.1.1.2 0 //表示禁止源IP地址为10.1.1.2的报文通过
rule 11 deny source 10.1.1.3 0 //表示拒绝源IP地址为10.1.1.3的报文通过
rule 15 permit source 10.1.1.0 0.0.0.255 //表示允许源IP地址为10.1.1.0网段地址的报文通过
```

试想一下，如果这条ACL的规则间隔不是5，而是1（rule 1、rule 2、rule 3...），这时再想插入新的规则，就只能先删除已有的规则，然后再配置新规则，最后将之前删除的规则重新配置还原。

因此，为了避免上述操作造成的麻烦，ACL引入了步长的概念。通过设置ACL步长，使规则之间留有一定的空间，就可以轻松的在旧规则中插入新规则了。

5.2.4 ACL 的匹配顺序

一条ACL可以由多条“deny | permit”语句组成，每一条语句描述一条规则，这些规则可能存在重复或矛盾的地方。例如，在一条ACL中先后配置以下两条规则：

```
rule deny ip destination 10.1.0.0 0.0.255.255 //表示拒绝目的IP地址为10.1.0.0/16网段地址的报文通过
rule permit ip destination 10.1.1.0 0.0.0.255 //表示允许目的IP地址为10.1.1.0/24网段地址的报文通过，该网段地址范围小于10.1.0.0/16网段范围
```

其中，permit规则与deny规则是相互矛盾的。对于目的IP=10.1.1.1的报文，如果系统先将deny规则与其匹配，则该报文会被拒绝通过。相反，如果系统先将permit规则与其匹配，则该报文会得到允许通过。

因此，对于规则之间存在重复或矛盾的情形，报文的匹配结果与ACL的匹配顺序是息息相关的。

设备支持两种ACL匹配顺序：配置顺序（**config**模式）和自动排序（**auto**模式）。缺省的ACL匹配顺序是**config**模式。

配置顺序

配置顺序，即系统按照ACL规则编号从小到大的顺序进行报文匹配，规则编号越小越容易被匹配。

- 如果配置规则时指定了规则编号，则规则编号越小，规则插入位置越靠前，该规则越先被匹配。
- 如果配置规则时未指定规则编号，则由系统自动为其分配一个编号。该编号是一个大于当前ACL内最大规则编号且是步长整数倍的最小整数，因此该规则会被最后匹配。

自动排序

自动排序，是指系统使用“深度优先”的原则，将规则按照精确度从高到低进行排序，并按照精确度从高到低的顺序进行报文匹配。规则中定义的匹配项限制越严格，规则的精确度就越高，即优先级越高，系统越先匹配。各类ACL的“深度优先”顺序匹配原则如表5-2所示。

关于表5-2中提到的IP地址通配符掩码、IP协议承载的协议类型、TCP/UDP端口号、二层协议类型通配符掩码、MAC地址通配符掩码等ACL匹配项的详细介绍，请参见[5.2.5 ACL的常用匹配项](#)。

表 5-2 “深度优先”匹配原则

ACL类型	匹配原则
基本 ACL&ACL 6	1. 先看规则中是否带VPN实例，带VPN实例的规则优先。 2. 再比较源IP地址范围，源IP地址范围小（IP地址通配符掩码中“0”位的数量多）的规则优先。 3. 如果源IP地址范围相同，则规则编号小的优先。
高级 ACL&ACL 6	1. 先看规则中是否带VPN实例，带VPN实例的规则优先。 2. 再比较协议范围，指定了IP协议承载的协议类型的规则优先。 3. 如果协议范围相同，则比较源IP地址范围，源IP地址范围小（IP地址通配符掩码中“0”位的数量多）的规则优先。 4. 如果协议范围、源IP地址范围相同，则比较目的IP地址范围，目的IP地址范围小（IP地址通配符掩码中“0”位的数量多）的规则优先。 5. 如果协议范围、源IP地址范围、目的IP地址范围相同，则比较四层端口号（TCP/UDP端口号）范围，四层端口号范围小的规则优先。 6. 如果上述范围都相同，则规则编号小的优先。
二层ACL	1. 先比较二层协议类型通配符掩码，通配符掩码大（协议类型通配符掩码中“1”位的数量多）的规则优先。 2. 如果二层协议类型通配符掩码相同，则比较源MAC地址范围，源MAC地址范围小（MAC地址通配符掩码中“1”位的数量多）的规则优先。 3. 如果源MAC地址范围相同，则比较目的MAC地址范围，目的MAC地址范围小（MAC地址通配符掩码中“1”位的数量多）的规则优先。 4. 如果源MAC地址范围、目的MAC地址范围相同，则规则编号小的优先。
用户ACL	1. 先比较协议范围，指定了IP协议承载的协议类型的规则优先。 2. 如果协议范围相同，则比较源IP地址范围。如果规则的源IP地址均为IP网段，则源IP地址范围小（IP地址通配符掩码中“0”位的数量多）的规则优先。 3. 如果协议范围、源IP地址范围相同，则比较目的IP地址范围。如果规则的目的IP地址均为IP网段，则目的IP地址范围小（IP地址通配符掩码中“0”位的数量多）的规则优先。 4. 如果协议范围、源IP地址范围、目的IP地址范围相同，则比较四层端口号（TCP/UDP端口号）范围，四层端口号范围小的规则优先。 5. 如果上述范围都相同，则规则编号小的优先。

在自动排序的ACL中配置规则时，不允许自行指定规则编号。系统能自动识别出该规则在这条ACL中对应的优先级，并为其分配一个适当的规则编号。

例如，在auto模式的高级ACL 3001中，先后配置以下两条规则：

```
rule deny ip destination 10.1.0.0 0.0.255.255 //表示拒绝目的IP地址为10.1.0.0/16网段地址的报文通过
rule permit ip destination 10.1.1.0 0.0.0.255 //表示允许目的IP地址为10.1.1.0/24网段地址的报文通过，该网段地址范围小于10.1.0.0/16网段范围
```

两条规则均没有带VPN实例，且协议范围、源IP地址范围相同，所以根据表5-2中高级ACL的深度优先匹配原则，接下来需要进一步比较规则的目的IP地址范围。由于permit

规则指定的目的地址范围小于deny规则，所以permit规则的精确度更高，系统为其分配的规则编号更小。配置完上述两条规则后，ACL 3001的规则排序如下：

```
#
acl number 3001 match-order auto
rule 5 permit ip destination 10.1.1.0 0.0.0.255
rule 10 deny ip destination 10.1.0.0 0.0.255.255
#
```

此时，如果再插入一条新的规则rule deny ip destination 10.1.1.1 0（目的IP地址范围是主机地址，优先级高于以上两条规则），则系统将按照规则的优先级关系，重新为各规则分配编号。插入新规则后，ACL 3001新的规则排序如下：

```
#
acl number 3001 match-order auto
rule 5 deny ip destination 10.1.1.1 0
rule 10 permit ip destination 10.1.1.0 0.0.0.255
rule 15 deny ip destination 10.1.0.0 0.0.255.255
#
```

相比config模式的ACL，auto模式ACL的规则匹配顺序更为复杂，但是auto模式ACL有其独特的应用场景。例如，在网络部署初始阶段，为了保证网络安全，管理员定义了较大的ACL匹配范围，用于丢弃不可信网段范围的所有IP报文。随着时间的推移，实际应用中需要允许这个大范围中某些特征的报文通过。此时，如果管理员采用的是auto模式，则只需要定义新的ACL规则，无需再考虑如何对这些规则进行排序避免报文被误丢弃。

5.2.5 ACL 的常用匹配项

设备支持的ACL匹配项种类非常丰富，其中最常用的匹配项包括以下几种。

生效时间段

格式：**time-range** *time-name*

所有ACL均支持根据生效时间段过滤报文。关于生效时间段的详细介绍，请参见[5.2.6 ACL的生效时间段](#)。

IP 承载的协议类型

格式：*protocol-number* | **icmp** | **tcp** | **udp** | **gre** | **igmp** | **ip** | **ipinip** | **ospf**

高级ACL支持基于协议类型过滤报文。常用的协议类型包括：ICMP（协议号1）、TCP（协议号6）、UDP（协议号17）、GRE（协议号47）、IGMP（协议号2）、IP（指任何IP层协议）、IPinIP（协议号4）、OSPF（协议号89）。协议号的取值可以是1～255。

例如，当设备某个接口下的用户存在大量的攻击者时，如果希望能够禁止这个接口下的所有用户接入网络，则可以通过指定协议类型为IP来屏蔽这些用户的IP流量来达到目的。配置如下：

```
rule deny ip //表示拒绝IP报文通过
```

再如，设备上打开透明防火墙功能后，在缺省情况下，透明防火墙会在域间丢弃所有入域间的报文，包括业务报文和协议报文。如果希望像OSPF这样的动态路由协议报文能正常通过防火墙，保证路由互通，这时，通过指定协议类型为OSPF即可解决问题。

```
rule permit ospf //表示允许OSPF报文通过
```

源/目的 IP 地址及其通配符掩码

源IP地址及其通配符掩码格式：**source** { *source-address source-wildcard* | **any** }

目的IP地址及其通配符掩码格式：**destination** { *destination-address destination-wildcard* | **any** }

基本ACL支持根据源IP地址过滤报文，高级ACL不仅支持源IP地址，还支持根据目的IP地址过滤报文。

将源/目的IP地址定义为规则匹配项时，需要在源/目的IP地址字段后面同时指定通配符掩码，用来与源/目的IP地址字段共同确定一个地址范围。

IP地址通配符掩码与IP地址的反向子网掩码类似，也是一个32比特位的数字字符串，用于指示IP地址中的哪些位将被检查。各比特位中，“0”表示“检查相应的位”，“1”表示“不检查相应的位”，概括为一句话就是“检查0，忽略1”。但与IP地址子网掩码不同的是，子网掩码中的“0”和“1”要求必须连续，而通配符掩码中的“0”和“1”可以不连续。

通配符掩码可以为0，相当于0.0.0.0，表示源/目的地址为主机地址；也可以为255.255.255.255，表示任意IP地址，相当于指定**any**参数。

举一个IP地址通配符掩码的示例，当希望来自192.168.1.0/24网段的所有IP报文都能够通过，可以配置如下规则：

```
rule 5 permit ip source 192.168.1.0 0.0.0.255
```

规则中的通配符掩码为0.0.0.255，表示只需检查IP地址的前三组二进制八位数对应的比特位。因此，如果报文源IP地址的前24个比特位与参照地址的前24个比特位（192.168.1）相同，即报文的源IP地址是192.168.1.0/24网段的地址，则允许该报文通过。[表5-3](#)展示了该例的地址范围计算过程。

表 5-3 通配符掩码示例

项目	十进制等价值	二进制等价值
参照地址	192.168.1.0	11000000.10101000.00000000 1.00000000
通配符掩码	0.0.0.255	00000000.00000000.00000000 0.11111111
确定的地址范围	192.168.1.* *表示0～255之间的整数	11000000.10101000.00000000 1.xxxxxxxx x既可以是0，也可以是1

更多的IP地址与通配符掩码共同确定的地址范围示例，详见[表5-4](#)。

表 5-4 IP 地址与通配符掩码共同确定的地址范围

IP地址	IP地址通配符掩码	确定的地址范围
0.0.0.0	255.255.255.255	任意IP地址
172.18.0.0	0.0.255.255	172.18.0.0/16网段的IP地址

IP地址	IP地址通配符掩码	确定的地址范围
172.18.5.2	0.0.0.0	仅172.18.5.2这一个主机地址
172.18.8.0	0.0.0.7	172.18.8.0/29网段的IP地址
172.18.8.8	0.0.0.7	172.18.8.8/29网段的IP地址
10.1.2.0	0.0.254.255（通配符掩码中的1和0不连续）	10.1.0.0/24 ~ 10.1.254.0/24网段之间且第三个字节为偶数的IP地址，如10.1.0.0/24、10.1.2.0/24、10.1.4.0/24、10.1.6.0/24等。

源/目的 MAC 地址及其通配符掩码

源MAC地址及其通配符掩码格式：**source-mac** *source-mac-address* [*source-mac-mask*]

目的地址及其通配符掩码格式：**destination-mac** *dest-mac-address* [*dest-mac-mask*]

仅二层ACL支持基于源/目的MAC地址过滤报文。

将源/目的MAC地址定义为规则匹配项时，可以在源/目的MAC地址字段后面同时指定通配符掩码，用来与源/目的MAC地址字段共同确定一个地址范围。

MAC地址通配符掩码的格式与MAC地址相同，采用十六进制数表示，共六个字节（48位），用于指示MAC地址中的哪些位将被检查。与IP地址通配符掩码不同的是，MAC地址通配符掩码各比特位中，1表示“检查相应的位”，0表示“不检查相应的位”。如果不指定通配符掩码，则默认掩码为ffff-ffff-ffff，表示检查MAC地址的每一位。

MAC地址与通配符掩码共同确定的地址范围示例，如表5-5所示。

表 5-5 MAC 地址与通配符掩码共同确定的地址范围

MAC地址	MAC地址通配符掩码	确定的地址范围
00e0-fc01-0101	0000-0000-0000	任意MAC地址
00e0-fc01-0101	ffff-ffff-ffff	仅00e0-fc01-0101这一个MAC地址
00e0-fc01-0101	ffff-ffff-0000	00e0-fc01-0000 ~ 00e0-fc01-ffff

VLAN 编号及其掩码

外层VLAN及其掩码格式：**vlan-id** *vlan-id* [*vlan-id-mask*]

二层ACL支持基于外层VLAN编号过滤报文。

将VLAN编号定义为规则匹配项时，可以在VLAN编号字段后面同时指定VLAN掩码，用来与VLAN编号字段共同确定一个VLAN范围。

VLAN掩码的格式是十六进制形式，取值范围是0x0 ~ 0xFFF。如果不指定VLAN掩码，则默认掩码为0xFFF，表示检查VLAN编号的每一位。

VLAN编号与掩码共同确定的VLAN范围示例，如表5-6所示。

表 5-6 VLAN 编号及其掩码共同确定的 VLAN 范围

VLAN编号	VLAN掩码	确定的VLAN范围
10	0x000	任意VLAN
10	0xFFF	仅VLAN 10
10	0xFF0	VLAN 1 ~ VLAN 15

TCP/UDP 端口号

源端口号格式：**source-port { eq port | gt port | lt port | range port-start port-end }**

目的端口号格式：**destination-port { eq port | gt port | lt port | range port-start port-end }**

在高级ACL中，当协议类型指定为TCP或UDP时，设备支持基于TCP/UDP的源/目的端口号过滤报文。

其中，TCP/UDP端口号的比较符含义如下：

- **eq port**: 指定等于源/目的端口。
- **gt port**: 指定大于源/目的端口。
- **lt port**: 指定小于源/目的端口。
- **range port-start port-end**: 指定源/目的端口的范围。*port-start*是端口范围的起始，*port-end*是端口范围的结束。

TCP/UDP端口号可以使用数字表示，也可以用字符串（助记符）表示。例如，**rule deny tcp destination-port eq 80**，可以用**rule deny tcp destination-port eq www**替代。常见TCP端口号及对应的字符串如表5-7所示，常见UDP端口号及对应的字符串如表5-8所示。

表 5-7 常见 TCP 端口号及对应的字符串

端口号	字符串	协议	说明
7	echo	Echo	Echo服务
9	discard	Discard	用于连接测试的空服务
13	daytime	Daytime	给请求主机发送日期和时间
19	CHARGen	Character generator	字符生成服务；发送无止境的字符流

端口号	字符串	协议	说明
20	ftp-data	FTP data connections	FTP数据端口
21	ftp	File Transfer Protocol(FTP)	文件传输协议（FTP）端口
23	telnet	Telnet	Telnet服务
25	smtp	Simple Mail Transport Protocol (SMTP)	简单邮件传输协议
37	time	Time	时间协议
43	whois	Nickname（WHOIS）	目录服务
49	tacacs	TAC Access Control System (TACACS)	用于基于TCP/IP验证和访问的访问控制系统（TACACS登录主机协议）
53	domain	Domain Name Service (DNS)	域名服务
70	gopher	Gopher	信息检索协议（互联网文档搜寻和检索）
79	finger	Finger	用于用户联系信息的Finger服务，查询远程主机在线用户等信息
80	www	World Wide Web (HTTP)	用于万维网（WWW）服务的超文本传输协议（HTTP），用于网页浏览
101	hostname	NIC hostname server	NIC机器上的主机名服务
109	pop2	Post Office Protocol v2	邮件协议-版本2
110	pop3	Post Office Protocol v3	邮件协议-版本3
111	sunrpc	Sun Remote Procedure Call (RPC)	SUN公司的远程过程调用（RPC）协议，用于远程命令执行，被网络文件系统（NFS）使用

端口号	字符串	协议	说明
119	nntp	Network News Transport Protocol (NNTP)	网络新闻传输协议，承载USENET通信
179	bgp	Border Gateway Protocol (BGP)	边界网关协议
194	irc	Internet Relay Chat (IRC)	互联网中继聊天（多线交谈协议）
512	exec	Exec (rsh)	用于对远程执行的进程进行验证
513	login	Login (rlogin)	远程登录
514	cmd	Remote commands	远程命令，不必登录的远程shell（rshell）和远程复制（rcp）
515	lpd	Printer service	打印机（lpr）假脱机
517	talk	Talk	远程对话服务和客户
540	uucp	Unix-to-Unix Copy Program	Unix到Unix复制服务
543	klogin	Kerberos login	Kerberos版本5（v5）远程登录
544	kshell	Kerberos shell	Kerberos版本5（v5）远程shell

表 5-8 常见 UDP 端口号及对应的字符串

端口号	字符串	协议	说明
7	echo	Echo	Echo服务
9	discard	Discard	用于连接测试的空服务
37	time	Time	时间协议
42	nameserver	Host Name Server	主机名服务
53	dns	Domain Name Service (DNS)	域名服务
65	tacacs-ds	TACACS-Database Service	TACACS数据库服务

端口号	字符串	协议	说明
67	bootps	Bootstrap Protocol Server	引导程序协议（BOOTP）服务端，DHCP服务使用
68	bootpc	Bootstrap Protocol Client	引导程序协议（BOOTP）客户端，DHCP客户使用
69	tftp	Trivial File Transfer Protocol (TFTP)	小文件传输协议
90	dnsix	DNSIX Security Attribute Token Map	DNSIX安全属性标记图
111	sunrpc	SUN Remote Procedure Call (SUN RPC)	SUN公司的远程过程调用（RPC）协议，用于远程命令执行，被网络文件系统（NFS）使用
123	ntp	Network Time Protocol (NTP)	网络时间协议，蠕虫病毒会利用
137	netbios-ns	NETBIOS Name Service	NETBIOS名称服务
138	netbios-dgm	NETBIOS Datagram Service	NETBIOS数据报服务
139	netbios-ssn	NETBIOS Session Service	NETBIOS会话服务
161	snmp	SNMP	简单网络管理协议
162	snmptrap	SNMPTRAP	SNMP陷阱
177	xdmcp	X Display Manager Control Protocol (XDMCP)	X显示管理器控制协议
434	mobileip-ag	MobileIP-Agent	移动IP代理
435	mobileip-mn	MobileIP-MN	移动IP管理
512	biff	Mail notify	异步邮件，可用来通知用户有邮件到达
513	who	Who	登录的用户列表
514	syslog	Syslog	UNIX系统日志服务
517	talk	Talk	远程对话服务器和客户端
520	rip	Routing Information Protocol	RIP路由协议

TCP 标志信息

格式：**tcp-flag { ack | established | fin | psh | rst | syn | urg }***

在高级ACL中，当协议类型指定为TCP时，设备支持基于TCP标志信息过滤报文。

TCP报文头有6个标志位：

- URG(100000)：标识紧急指针有效
- ACK(010000)：标识确认序号有效
- PSH(001000)：标识接收方应该尽快将这个报文段上交给应用层
- RST(000100)：标识重建连接
- SYN(000010)：同步序号，用来发起一个连接
- FIN(000001)：标识发送方完成发送任务

TCP标志信息中的**established**，表示标志位为ACK(010000)或RST(000100)。

指定**tcp-flag**的ACL规则可以用来实现单向访问控制。假设，要求192.168.1.0/24网段用户可以主动访问192.168.2.0/24网段用户，但反过来192.168.2.0/24网段用户不能主动访问192.168.1.0/24。可通过在设备上连接192.168.2.0/24网段的接口入方向上，应用ACL规则来实现该需求。

由TCP建立连接和关闭连接的过程可知，只有在TCP中间连接过程的报文才会ACK=1或者RST=1。根据这个特点，配置如下两种ACL规则，允许TCP中间连接过程的报文通过，拒绝该网段的其他TCP报文通过，就可以限制192.168.2.0/24网段主动发起的TCP连接。

- 类型一：配置指定**ack**和**rst**参数的ACL规则

```
rule 5 permit tcp source 192.168.2.0 0.0.0.255 tcp-flag ack //允许ACK=1的TCP报文通过
rule 10 permit tcp source 192.168.2.0 0.0.0.255 tcp-flag rst //允许RST=1的TCP报文通过
rule 15 deny tcp source 192.168.2.0 0.0.0.255 //拒绝该网段的其他TCP报文通过
```

- 类型二：配置指定**established**参数的ACL规则

```
rule permit tcp source 192.168.2.0 0.0.0.255 tcp-flag established // established表示ACK=1或者RST=1，
表示允许TCP中间连接过程的报文通过
rule deny tcp source 192.168.2.0 0.0.0.255 //拒绝该网段的其他TCP报文通过
```

IP 分片信息

格式：**none-first-fragment**

基本ACL和高级ACL支持基于IP分片信息过滤报文。

IP分片除了首片报文外，还有后续分片报文，又叫做非首片分片报文。仅首片分片报文携带四层信息（如TCP/UDP端口号等），后续分片报文均不携带。网络设备收到分片报文后，会判断其是否是最后一个分片报文。如果不是，则为其分配内存空间，以便于最后一个分片报文到达后完成重组。黑客可以利用这一点，向接收方设备发起分片报文攻击，始终不向接收方发送最后一个分片报文，使得接收方的内存得不到及时释放（接收方会启动一个分片重组的定时器，在定时器超时前如果无法完成重组，将向发送方发送ICMP重组超时差错报文；如果定时器超时后仍未完成重组，则丢弃已存储的分片报文）。在分片报文发送数量很多并且发送速度很快的情况下，接收方的内存很容易被占满，从而导致接收方没有足够的内存资源处理其他正常的业务。

为了解决这个问题，可以配置指定**none-first-fragment**匹配项的ACL规则来阻塞非首片分片报文，从而达到防范分片报文攻击的目的。

针对非分片报文、首片分片报文、非首片分片报文这三类报文，ACL的处理方式如表5-9所示。

表 5-9 ACL 对 IP 分片报文的处理方式

规则包含的匹配项	非分片报文	首片分片报文	非首片分片报文
三层信息（如源/目的IP地址）	三层信息匹配上，则返回匹配结果（permit/deny）；未匹配上，则转下一条规则进行匹配	三层信息匹配上，则返回匹配结果（permit/deny）；未匹配上，则转下一条规则进行匹配	三层信息匹配上，则返回匹配结果（permit/deny）；未匹配上，则转下一条规则进行匹配
三层信息 + 四层信息（如TCP/UDP端口号）	三层和四层信息都匹配上，则返回匹配结果（permit/deny）；未匹配上，则转下一条规则进行匹配	三层和四层信息都匹配上，则返回匹配结果（permit/deny）；未匹配上，则转下一条规则进行匹配	不匹配，转下一条规则进行匹配
三层信息 + none-first-fragment	不匹配，转下一条规则进行匹配	不匹配，转下一条规则进行匹配	三层信息匹配上，则返回匹配结果（permit/deny）；未匹配上，则转下一条规则进行匹配

例如，ACL 3012中存在以下规则：

```
#
acl number 3012
rule 5 deny tcp destination 192.168.2.2 0 none-first-fragment
rule 10 permit tcp destination 192.168.2.2 0 destination-port eq www
rule 15 deny ip
#
```

- 该报文是非分片报文或首片分片报文时：如果该报文的端口号是80（www对应的端口号是80），则报文与rule 10匹配，报文被允许通过；如果该报文的端口号不是80，则报文与rule 15匹配，报文被拒绝通过。
- 该报文是非首片分片报文时：该报文与rule 5匹配，报文被拒绝通过。

5.2.6 ACL 的生效时间段

产生背景

ACL定义了丰富的匹配项，可以满足大部分的报文过滤需求。但需求是不断变化发展的，新的需求总是不断涌现。例如，某公司要求，在上班时间只允许员工浏览与工作相关的几个网站，下班或周末时间才可以访问其他互联网网站；再如，在每天20:00～22:00的网络流量的高峰期，为防止P2P、下载类业务占用大量带宽对其他数据业务的正常使用造成影响，需要对P2P、下载类业务的带宽进行限制。

基于时间的ACL过滤就是用来解决上述问题的。管理员可以根据网络访问行为的要求和网络的拥塞情况，配置一个或多个ACL生效时间段，然后在ACL规则中引用该时间段，从而实现在不同的时间段设置不同的策略，达到网络优化的目的。

生效时间段模式

在ACL规则中引用的生效时间段存在两种模式：

- 第一种模式——周期时间段：以星期为参数来定义时间范围，表示规则以一周为周期（如每周一的8至12点）循环生效。

格式：**time-range** *time-name* **start-time to end-time** { *days* } &<1-7>

- *time-name*: 时间段名称，以英文字母开头的字符串。
- **start-time to end-time**: 开始时间和结束时间。格式为[小时:分钟] to [小时:分钟]。
- *days*: 有多种表达方式。
 - **Mon、Tue、Wed、Thu、Fri、Sat、Sun**中的一个或者几个的组合，也可以用数字表达，0表示星期日，1表示星期一，.....6表示星期六。
 - **working-day**: 从星期一到星期五，五天。
 - **daily**: 包括一周七天。
 - **off-day**: 包括星期六和星期日，两天。

- 第二种模式——绝对时间段：从某年某月某日的某一时间开始，到某年某月某日的某一时间结束，表示规则在这段时间范围内生效。

格式：**time-range** *time-name* **from time1 date1 [to time2 date2]**

- *time-name*: 时间段名称，以英文字母开头的字符串。
- *time1/time2*: 格式为[小时:分钟]。
- *date1/date2*: 格式为[YYYY/MM/DD]，表示年/月/日。

可以使用同一名称（*time-name*）配置内容不同的多条时间段，配置的各周期时间段之间以及各绝对时间段之间的交集将成为最终生效的时间范围。

例如，在ACL 2001中引用了时间段“test”，“test”包含了三个生效时间段：

```
#
time-range test 8:00 to 18:00 working-day
time-range test 14:00 to 18:00 off-day
time-range test from 00:00 2014/01/01 to 23:59 2014/12/31
#
acl number 2001
rule 5 permit time-range test
```

- 第一个时间段，表示在周一到周五每天8:00到18:00生效，这是一个周期时间段。
- 第二个时间段，表示在周六、周日下午14:00到18:00生效，这是一个周期时间段。
- 第三个时间段，表示从2014年1月1日00:00起到2014年12月31日23:59生效，这是一个绝对时间段。

时间段“test”最终描述的时间范围为：2014年的周一到周五每天8:00到18:00以及周六和周日下午14:00到18:00。

5.2.7 ACL 应用模块的 ACL 默认动作和处理机制

ACL 的应用模块

配置完ACL后，必须在具体的业务模块中应用ACL，才能使ACL正常下发和生效。

最基本的ACL应用方式，是在简化流策略/流策略中应用ACL，使设备能够基于全局或接口下发ACL，实现对转发报文的过滤。此外，ACL还可以应用在Telnet、FTP、路由等模块。

如表5-10所示，ACL应用的业务模块，主要分为以下几类。

表 5-10 ACL 应用的业务模块

业务分类	应用场景	涉及业务模块
对转发的报文进行过滤	基于全局和接口，对转发的报文进行过滤，从而使设备能够进一步对过滤出的报文进行丢弃、修改优先级、重定向等处理。 例如，可以利用ACL，降低P2P下载、网络视频等消耗大量带宽的数据流的服务等级，在网络拥塞时优先丢弃这类流量，减少它们对其他重要流量的影响。	简化流策略/流策略
对上送CPU处理的报文进行过滤	对上送CPU的报文进行必要的限制，可以避免CPU处理过多的协议报文造成占用率过高、性能下降。 例如，当发现某用户向设备发送大量的ARP攻击报文，造成设备CPU繁忙，引发系统中断时，可以在本机防攻击策略的黑名单中应用ACL，将该用户加入黑名单，使CPU丢弃该用户发送的报文。	黑名单
登录控制	对设备的登录权限进行控制，允许合法用户登录，拒绝非法用户登录，从而有效防止未经授权用户的非法接入，保证网络安全。 例如，一般情况下设备只允许管理员登录，非管理员用户不允许随意登录。这时就可以在Telnet中应用ACL，并在ACL中定义哪些主机可以登录，哪些主机不能。	Telnet、STelnet、FTP、SFTP、HTTP、SNMP

业务分类	应用场景	涉及业务模块
路由过滤	ACL可以应用在各种动态路由协议中，对路由协议发布、接收的路由信息以及组播组进行过滤。 例如，可以将ACL和路由策略配合使用，禁止设备将某网段路由发给邻居路由器。	BGP、IS-IS、OSPF、OSPFv3、RIP、RIPng、组播协议

应用模块的 ACL 默认动作和处理机制

在各类业务模块中应用ACL时，ACL的默认动作各有不同，所以各业务模块对命中/未命中ACL规则报文的处理机制也各不相同。

例如，流策略中的ACL默认动作是permit，在流策略中应用ACL时，如果ACL中存在规则但报文未匹配上，该报文仍可以正常通过。而Telnet中的ACL默认动作是deny，在Telnet中应用ACL时，如果遇到此种情况，该报文会被拒绝通过。

此外，黑名单模块中的ACL处理机制与其他模块有所不同。在黑名单中应用ACL时，无论ACL规则配置成permit还是deny，只要报文命中了规则，该报文都会被系统丢弃。

各类业务模块中的ACL默认动作及ACL处理机制，如表5-11所示。

表 5-11 各业务模块的 ACL 默认动作及 ACL 处理机制

业务模块	ACL默认动作	ACL处理机制				
		命中 permit 规则	命中deny 规则	ACL 中配置了规则，但未命中任何规则	ACL中未配置规则	ACL未创建
Telnet	deny	permit（允许登录）	deny（拒绝登录）	deny（拒绝登录）	permit（允许登录）	permit（允许登录）
STelnet	deny	permit（允许登录）	deny（拒绝登录）	deny（拒绝登录）	permit（允许登录）	permit（允许登录）

业务模块	ACL默认动作	ACL处理机制				
		命中 permit 规则	命中deny 规则	ACL 中配置了 规则， 但未命中 任何规则	ACL中 未配置 规则	ACL未 创建
HTTP	permit	permit （允许 登录）	deny（拒 绝登录）	permi t（允 许登 录）	permit （允许 登录）	permit （允许 登录）
SNMP	deny	permit （允许 登录）	deny（拒 绝登录）	deny （拒 绝登 录）	permit （允许 登录）	permit （允许 登录）
FTP	deny	permit （允许 登录）	deny（拒 绝登录）	deny （拒 绝登 录）	permit （允许 登录）	permit （允许 登录）
TFTP	deny	permit （允许 登录）	deny（拒 绝登录）	deny （拒 绝登 录）	permit （允许 登录）	permit （允许 登录）
SFTP	deny	permit （允许 登录）	deny（拒 绝登录）	deny （拒 绝登 录）	permit （允许 登录）	permit （允许 登录）

业务模块	ACL默认动作	ACL处理机制				
		命中 permit 规则	命中deny 规则	ACL 中配置了 规则， 但未命中 任何规则	ACL中 未配置 规则	ACL未 创建
流策略	permit	- 流行为是permit时：permit（允许通过） - 流行为是deny时：deny（丢弃报文） - 流行为是其他动作时：permit（执行流策略动作）	deny(丢弃报文) 说明 报文命中deny规则时，只有在流行为是流量统计或流镜像的情况下，设备才会执行流行为动作，否则流行为动作不生效。	permit（功能不生效，按照原转发方式进行转发）	permit（功能不生效，按照原转发方式进行转发）	permit（功能不生效，按照原转发方式进行转发）

业务模块	ACL默认动作	ACL处理机制				
		命中 permit 规则	命中deny 规则	ACL 中配置了 规则， 但未命中 任何规则	ACL中 未配置 规则	ACL未 创建
简化流策略	permit	permit （执行 简化流 策略动 作）	- 简化流策略动作作为报文过滤（traffic-filter或traffic-secure）时:deny（丢弃报文） 说明 主机发出的报文，可以匹配上策略，但是不做丢弃处理。 - 简化流策略动作作为其他动作时: permit（执行简化流策略动作）	permit（功能不生效，按照原转发方式进行转发）	permit（功能不生效，按照原转发方式进行转发）	permit（功能不生效，按照原转发方式进行转发）

业务模块		ACL默认动作	ACL处理机制				
			命中 permit 规则	命中deny 规则	ACL 中配置了 规则， 但未命中 任何规则	ACL中 未配置 规则	ACL未 创建
本机防攻击策略（黑名单）		permit	deny(丢弃报文)	deny(丢弃报文)	permit（功能不生效，正常上送报文）	permit（功能不生效，正常上送报文）	permit（功能不生效，正常上送报文）
NAT Server		permit	permit（做地址转换）	deny（不做地址转换）	deny（不做地址转换）	permit（做地址转换）	permit（做地址转换）
路由	Route Policy	deny	- 匹配模式是 permit 时：permit(允许执行路由策略) - 匹配模式是 deny 时：deny(不允许执行路由策略)	deny（功能不生效，不允许执行路由策略）	deny（功能不生效，不允许执行路由策略）	permit（对经过的所有路由生效）	deny（功能不生效，不允许执行路由策略）

业务模块		ACL默认动作	ACL处理机制				
			命中 permit 规则	命中deny 规则	ACL 中配置了 规则， 但未命中 任何规则	ACL中 未配置 规则	ACL未 创建
	Filter Policy	deny	permit（允许发布或接收该路由）	deny（不允许发布或接收该路由）	deny（不允许发布或接收该路由）	deny（不允许发布或接收该路由）	permit（允许发布或接收该路由）
组播	igmp-snooping ssm-policy	deny	permit(允许加入SSM组播组范围)	deny(禁止加入SSM组地址范围)	deny(禁止加入SSM组地址范围)	deny（禁止加入SSM组地址范围，所有组都不在SSM组地址范围内）	deny(禁止加入SSM组地址范围，只有临时组地址范围232.0.0.0～232.255.255.255在SSM组地址范围内)
	igmp-snooping group-policy	permit	permit(允许加入组播组)	deny(禁止加入组播组)	permit（允许加入组播组）	permit（允许加入组播组）	permit（允许加入组播组）

5.2.8 ACL 的常用配置原则

配置ACL规则时，可以遵循以下原则：

1. 如果配置的ACL规则存在包含关系，应注意严格条件的规则编号需要排序靠前，宽松条件的规则编号需要排序靠后，避免报文因命中宽松条件的规则而停止往下继续匹配，从而使其无法命中严格条件的规则。
2. 根据各业务模块ACL默认动作（请参见[5.2.7 ACL应用模块的ACL默认动作和处理机制](#)）的不同，ACL的配置原则也不同。例如，在默认动作为permit的业务模块中，如果只希望deny部分IP地址的报文，只需配置具体IP地址的deny规则，结尾无需添加任意IP地址的permit规则；而默认动作为deny的业务模块恰与其相反。详细的ACL常用配置原则，如[表5-12](#)所示。

 说明

以下rule的表达方式仅是示意形式，实际配置方法请参考各类ACL规则的命令行格式。

- **rule permit xxx/rule permit xxxx**：表示允许指定的报文通过，xxx/xxxx表示指定报文的标识，可以是源IP地址、源MAC地址、生效时间段等。xxxx表示的范围与xxx表示的范围是包含关系，例如xxx是某一个IP地址，xxxx可以是该IP地址所在的网段地址或any（表示任意IP地址）；再如xxx是周六的某一个时段，xxxx可以是双休日全天时间或一周七天全部时间。
- **rule deny xxx/rule deny xxxx**：表示拒绝指定的报文通过。
- **rule permit**：表示允许所有报文通过。
- **rule deny**：表示拒绝所有报文通过。

表 5-12 ACL 的常用配置原则

业务模块的ACL默认动作	permit所有报文	deny所有报文	permit少部分报文，deny大部分报文	deny少部分报文，permit大部分报文
permit	无需应用ACL	配置rule deny	需先配置rule permit xxx，再配置rule deny xxxx或rule deny 说明 以上原则适用于报文过滤的情形。当ACL应用于流策略中进行流量监管或者流量统计时，如果仅希望对指定的报文进行限速或统计，则只需配置rule permit xxx。	只需配置rule deny xxx，无需再配置rule permit xxxx或rule permit 说明 如果配置rule permit并在流策略中应用ACL，且该流策略的流行为behavior配置为deny，则设备会拒绝所有报文通过，导致全部业务中断。
deny	• 路由和组播模块：需配置rule permit • 其他模块：无需应用ACL	• 路由和组播模块：无需应用ACL • 其他模块：需配置rule deny	只需配置rule permit xxx，无需再配置rule deny xxxx或rule deny	需先配置rule deny xxx，再配置rule permit xxxx或rule permit

举例：

- 例1：在流策略中应用ACL，使设备对192.168.1.0/24网段的报文进行过滤，拒绝192.168.1.2和192.168.1.3主机地址的报文通过，允许192.168.1.0/24网段的其他地址的报文通过。

流策略的ACL默认动作为**permit**，该例属于“deny少部分报文，permit大部分报文”的情况，所以只需配置**rule deny xxx**。

```
#
acl number 2000
rule 5 deny source 192.168.1.2 0
rule 10 deny source 192.168.1.3 0
#
```

- 例2：在流策略中应用ACL，使设备对192.168.1.0/24网段的报文进行过滤，允许192.168.1.2和192.168.1.3主机地址的报文通过，拒绝192.168.1.0/24网段的其他地址的报文通过。

流策略的ACL默认动作为**permit**，该例属于“permit少部分报文，deny大部分报文”的情况，所以需先配置**rule permit xxx**，再配置**rule deny xxxx**。

```
#
acl number 2000
rule 5 permit source 192.168.1.2 0
rule 10 permit source 192.168.1.3 0
rule 15 deny source 192.168.1.0 0.0.0.255
#
```

- 例3：在Telnet中应用ACL，仅允许管理员主机（IP地址为172.16.105.2）能够Telnet登录设备，其他用户不允许Telnet登录。

Telnet的ACL默认动作为**deny**，该例属于“permit少部分报文，deny大部分报文”的情况，所以只需配置**rule permit xxx**。

```
#
acl number 2000
rule 5 permit source 172.16.105.2 0
#
```

- 例4：在Telnet中应用ACL，不允许某两台主机（IP地址为172.16.105.3和172.16.105.4）Telnet登录设备，其他用户均允许Telnet登录。

Telnet的ACL默认动作为**deny**，该例属于“deny少部分报文，permit大部分报文”的情况，所以需先配置**rule deny xxx**，再配置**rule permit**。

```
#
acl number 2000
rule 5 deny source 172.16.105.3 0
rule 10 deny source 172.16.105.4 0
rule 15 permit
#
```

- 例5：在FTP中应用ACL，不允许用户在周六的00:00～8:00期间访问FTP服务器，允许用户在其他任意时间访问FTP服务器。

FTP的ACL默认动作为**deny**，该例属于“deny少部分报文，permit大部分报文”的情况，所以需先配置**rule deny xxx**，再配置**rule permit xxxx**。

```
#
time-range t1 00:00 to 08:00 Sat
time-range t2 00:00 to 23:59 daily
#
acl number 2000
rule 5 deny time-range t1
rule 10 permit time-range t2
#
```

5.3 ACL 应用场景

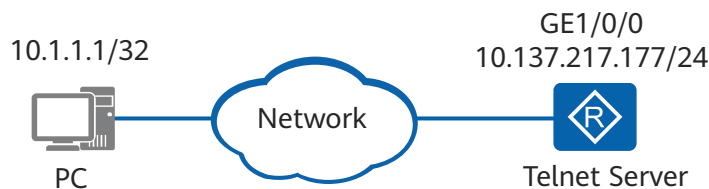
介绍ACL的应用场景。

5.3.1 使用 ACL 限制 Telnet 登录权限

ACL应用在Telnet模块中，可以使设备作为Telnet服务器时，对哪些Telnet客户端以Telnet方式登录到本设备能加以控制，从而有效防止未经授权用户的非法接入。

如图5-4所示，为简单而方便的配置和管理远程设备（Telnet Server），管理员在服务器端进行了配置，使Telnet用户必须使用AAA认证方式才能登录。同时，管理员配置了基于ACL的登录限制策略，保证只有管理员使用的PC才能登录该设备。

图 5-4 使用 ACL 限制 Telnet 登录权限

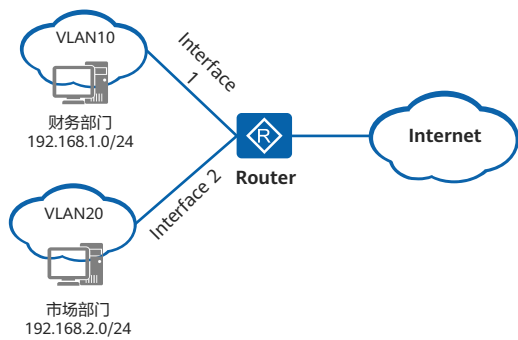


5.3.2 使用 ACL 限制不同网段用户的互访

ACL应用在QoS的流策略/简化流策略中，可以实现不同网段用户之间访问权限的限制，从而避免用户之间随意访问形成安全隐患。

如图5-5所示，某公司为财务部和市场部规划了两个网段的IP地址。为了避免两个部门之间相互访问造成公司机密的泄露，管理员在两个部门连接Router的接口（Interface1和Interface2）的入方向上应用绑定了ACL的流策略/简化流策略，禁止两个部门的互访。

图 5-5 使用 ACL 限制不同网段用户的互访

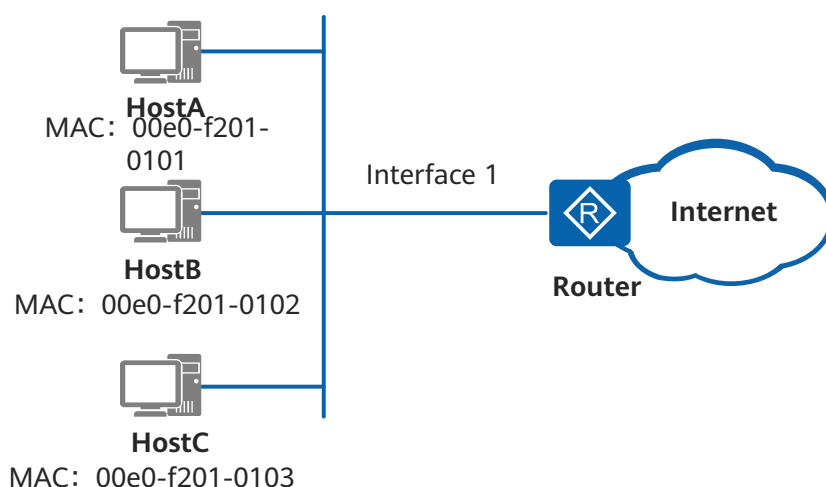


5.3.3 使用 ACL 禁止特定用户主机在特定时间内上网

ACL应用在QoS的流策略/简化流策略中，可以实现特定用户主机在特定时间范围内上网权限的限制。

如图5-6所示，某公司通过router连接到Internet。部分员工经常在上班时间访问与工作无关的网站，工作效率低下。所以，管理员配置了基于时间的ACL，并在这些用户连接router的接口（Interface 1）的入方向上应用绑定了ACL的流策略/简化流策略，禁止这些用户在工作时间内上网，其余时间均可以上网。

图 5-6 使用 ACL 禁止特定用户在特定时间内上网

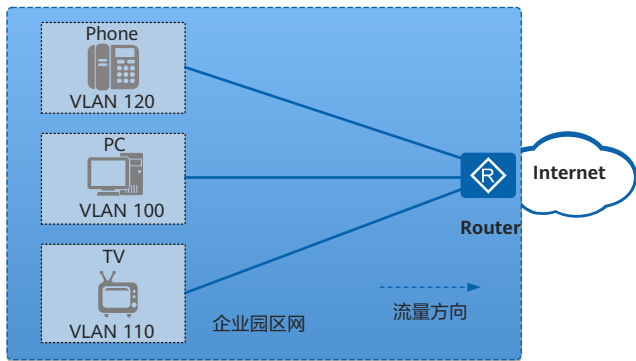


5.3.4 在 QoS 中使用 ACL 实施流量监管

ACL应用在QoS的流策略/简化流策略中，可以实现对不同流量进入网络的速率的监督，对超出部分的流量进行“惩罚”，使进入的流量被限制在一个合理的范围之内，从而保护网络资源和用户的利益。

如图5-7所示，某公司的数据业务、视频业务、语音业务分别属于VLAN 100、VLAN 110、VLAN120。由于语音业务对服务质量的要求最高，视频业务次之，数据业务要求最低，所以管理员配置了基于ACL的流量监管功能，使设备可以对该公司不同的业务流按照VLAN ID进行分类，并对匹配ACL规则的报文进行限速，从而将不同业务的流量限制在一个合理的范围之内，保证各业务的带宽需求。

图 5-7 在 QoS 中使用 ACL 实施流量监管



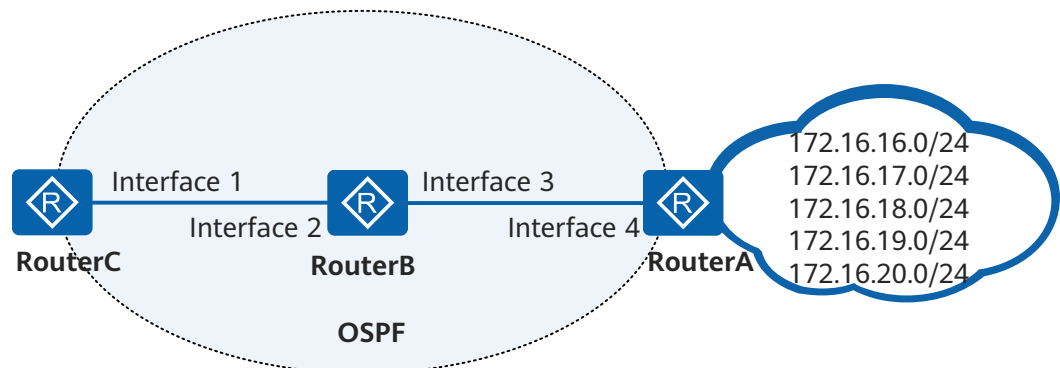
5.3.5 在 OSPF 中使用 ACL 过滤路由信息

ACL可以应用在各种动态路由协议中，对路由协议发布和接收的路由信息进行过滤。

如图5-8所示，在运行OSPF（Open Shortest Path First）协议的网络中，RouterA从Internet网络接收路由，并为OSPF网络提供了Internet路由。现要求OSPF网络中只能访问172.16.17.0/24、172.16.18.0/24和172.16.19.0/24三个网段的网络，其中RouterC连接的网段只能访问172.16.18.0/24网段的网络。

管理员可以在RouterA上配置ACL和路由策略，使其在路由发布时运用路由策略，仅提供路由172.16.17.0/24、172.16.18.0/24、172.16.19.0/24给RouterB，实现OSPF网络中只能访问172.16.17.0/24、172.16.18.0/24和172.16.19.0/24三个网段的网络；并且在RouterC上配置ACL和路由策略，使其在路由引入时运用路由策略，仅接收路由172.16.18.0/24，实现RouterC连接的网段只能访问172.16.18.0/24网段的网络。

图 5-8 在 OSPF 中使用 ACL 过滤路由信息

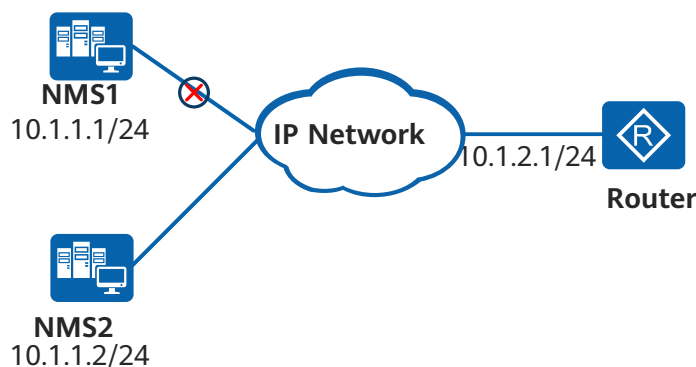


5.3.6 在 SNMP 中使用 ACL 过滤非法网管

ACL应用在SNMP模块中，可以使网管对设备的管理权限得到控制，从而有效防止非法网管操作设备。

如图5-9所示，为简单而方便的配置和管理远程设备（Router），管理员在Router上配置了SNMP Agent服务，Agent及时地向网管报告设备的当前状态信息，使网管可以远端控制设备。同时，管理员配置了基于ACL的网管访问权限限制，保证只有可信任的网管（NMS2）才能管理该设备。

图 5-9 SNMP 中应用 ACL 过滤非法网管



5.3.7 在 NAT 中使用 ACL 过滤流量

ACL可以应用在NAT过滤功能中，让NAT设备对外网发送到内网的流量进行过滤。

NAT过滤是指NAT设备对外网发到内网的流量进行过滤，包括三种类型：

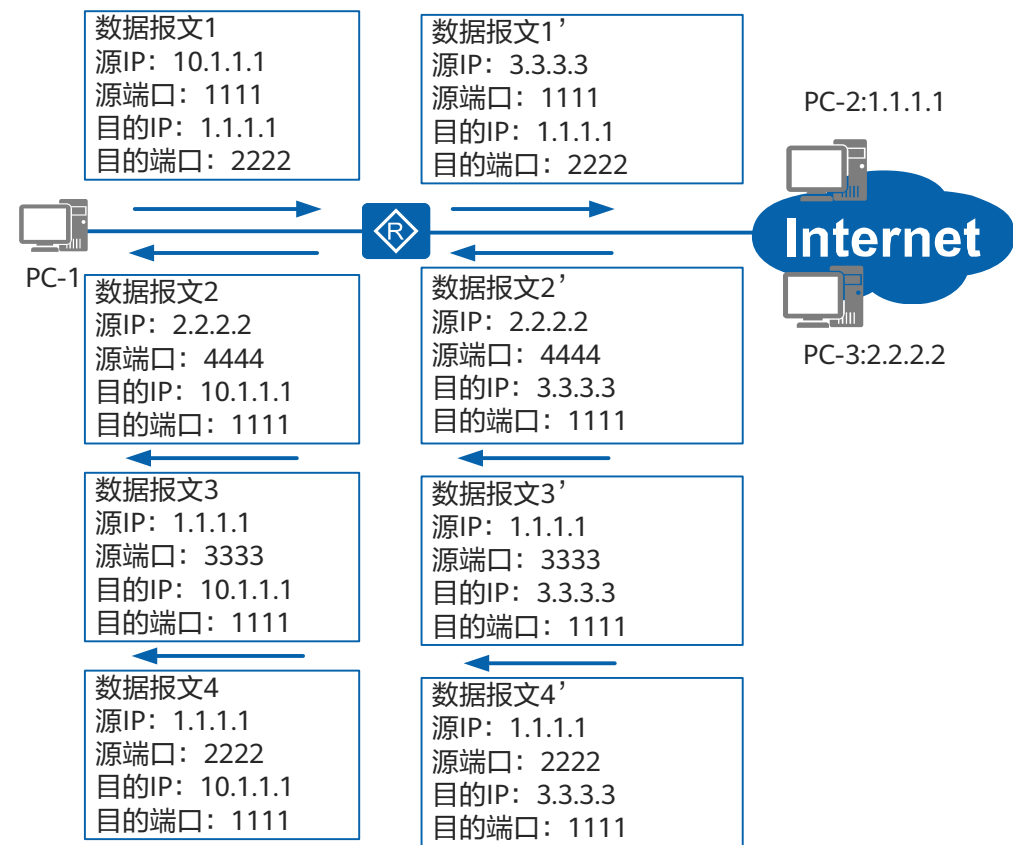
- 与外部地址无关的NAT过滤行为
- 与外部地址相关的NAT过滤行为
- 与外部地址和端口都相关的NAT过滤行为

如图5-10所示，私网用户PC-1通过NAT设备与外网用户PC-2、PC-3进行通信。数据报文1代表私网主机PC-1访问公网主机PC-2，PC-1使用的端口号为1111，访问PC-2的端口2222；经过NAT设备时，源IP转换为10.169.10.1。

当私网主机向某公网主机发起访问后，公网主机发向私网主机的流量经过NAT设备时需要进行过滤。数据报文2'、数据报文3'和数据报文4'代表三种场景，分别对应上述三种NAT过滤类型：

- 数据报文2'代表公网主机PC-3（与报文1的目的地址不同）访问私网主机PC-1，目的端口号为1111，只有配置了外部地址无关的NAT过滤行为，才允许此报文通过，否则被NAT设备过滤掉。
- 数据报文3'代表公网服务器PC-2（与报文1的目的地址相同）访问私网主机PC-1，目的端口号为1111，源端口号为3333（与报文1的目的端口不同），只有配置了外部地址相关的NAT过滤行为或者配置了外部地址无关的NAT过滤行为，才允许此报文通过，否则被NAT设备过滤掉。
- 数据报文4'代表公网服务器PC-2（与报文1的目的地址相同）访问私网主机PC-1，目的端口号为1111，源端口号为2222（与报文1的目的端口相同），这属于外部地址和端口都相关的NAT过滤行为，是缺省的过滤行为，不配置或者配置任何类型的NAT过滤行为，都允许此报文通过，不会被过滤掉。

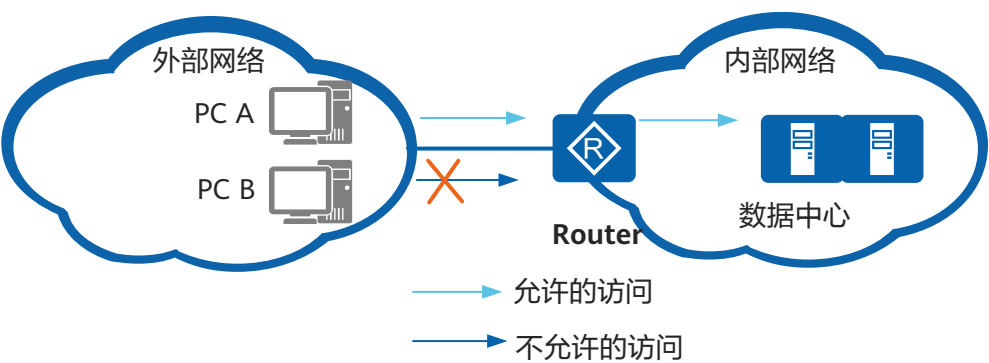
图 5-10 在 NAT 中使用 ACL 过滤流量



5.3.8 在防火墙中使用 ACL 防止外网入侵内网

防火墙用在内外网络边缘处，防止外部网络对内部网络的入侵，也可以用来保护网络内部大型机和重要的资源（如数据）。

图 5-11 在防火墙中使用 ACL



如图5-11所示，只允许外部特定主机PC A访问内部网络中的数据中心，别的访问都不允许。在Router上部署防火墙并配置ACL，就可以达到这个要求。

5.4 ACL 配置任务概览

设备支持的ACL主要包括：基本ACL、高级ACL、二层ACL、用户ACL、基本ACL6和高级ACL6。

ACL的配置任务如表5-13所示。各配置任务之间，是并列关系，至少要选择其中的一种ACL进行配置。

表 5-13 ACL 配置任务概览

场景	描述	对应任务
配置并应用基本ACL	基本ACL根据源IP地址、分片信息和生效时间段等信息来定义规则，对IPv4报文进行过滤。 如果只需要根据源IP地址对报文进行过滤，可以配置基本ACL。	5.7.1 配置并应用基本ACL
配置并应用高级ACL	高级ACL根据源IP地址、目的IP地址、IP协议类型、TCP源/目的端口、UDP源/目的端口号、分片信息和生效时间段等信息来定义规则，对IPv4报文进行过滤。 高级ACL比基本ACL提供了更准确、丰富、灵活的规则定义方法。例如，当希望同时根据源IP地址和目的IP地址对报文进行过滤时，则需要配置高级ACL。	5.7.2 配置并应用高级ACL
配置并应用二层ACL	二层ACL根据以太网帧头信息来定义规则，如源MAC（Media Access Control）地址、目的MAC地址、VLAN、二层协议类型等，对IPv4和IPv6报文进行过滤。 如果只需要根据二层信息过滤报文，可以配置二层ACL。	5.7.3 配置并应用二层ACL

场景	描述	对应任务
配置并应用用户ACL	用户ACL根据IPv4报文的源IP地址、目的IP地址、IP协议类型、ICMP类型、TCP源端口/目的端口、UDP源端口/目的端口号、生效时间段等来定义规则，对IPv4报文进行过滤。 如果需要配置Portal用户的免认证规则，可以配置用户ACL。	5.7.4 配置并应用用户ACL
配置并应用基本ACL6	基本ACL6根据源IPv6地址、分片信息和生效时间段等信息来定义规则，对IPv6报文进行过滤。 如果只需要根据源IPv6地址对报文进行过滤，可以配置基本ACL6。	5.7.5 配置并应用基本ACL6
配置并应用高级ACL6	高级ACL6根据源IPv6地址、目的IPv6地址、IPv6协议类型、TCP源/目的端口号、UDP源/目的端口号、分片信息和生效时间段等信息来定义规则，对IPv6报文进行过滤。 高级ACL6比基本ACL6提供了更准确、丰富、灵活的规则定义方法。例如，当希望同时根据源IPv6地址和目的IPv6地址对报文进行过滤时，则需要配置高级ACL6。	5.7.6 配置并应用高级ACL6

5.5 ACL 配置注意事项

介绍ACL的配置注意事项。

涉及网元

无需其他网元配合。

License 支持

ACL特性是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

对于设备上的单板而言，仅8FE1GE单板支持二层转发流量的ACL。

特性依赖和限制

无

5.6 ACL 缺省配置

介绍ACL缺省配置，实际应用的配置可以基于缺省配置进行修改。

ACL的缺省配置如表5-14所示。

表 5-14 ACL 缺省配置

参数	缺省值
规则步长	5
匹配顺序	配置顺序

5.7 配置 ACL

介绍ACL详细的配置过程。

5.7.1 配置并应用基本 ACL

5.7.1.1 （可选）配置 ACL 的生效时间段

背景信息

缺省情况下，ACL一旦被应用到业务模块后是一直生效的。通过定义生效时间段，并将时间段与ACL规则关联，可以使ACL规则在某段时间范围内生效，从而达到使用[基于时间的ACL](#)来控制业务的目的。例如，在上班时间禁止员工访问互联网网站，避免影响工作；在网络流量高峰期，限制P2P/下载类业务的带宽，避免网络拥塞等。

在ACL规则中引用的生效时间段存在两种模式：

- 第一种模式——周期时间段：以星期为参数来定义时间范围，表示规则以一周为周期（如每周一的8点至12点）循环生效。
- 第二种模式——绝对时间段：从某年某月某日的某一时间开始，到某年某月某日的某一时间结束，表示规则在这段时间范围内生效。

说明

为避免设备的系统时间与网络不同步造成ACL不生效，建议配置NTP（Network Time Protocol），实现系统时钟的自动同步，保证设备与网络中所有设备时钟的一致性。NTP的配置，请参见《AR300, AR700 配置指南-设备管理》中的“配置NTP基本功能”。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**time-range time-name { start-time to end-time { days } &<1-7> | from time1 date1 [to time2 date2] }**，创建一个时间段。

缺省情况下，设备没有配置时间段。

可以使用同一名称（*time-name*）配置内容不同的多条时间段，配置的各周期时间段之间以及各绝对时间段之间的交集将成为最终生效的时间范围。

如果要删除时间段，可参见[删除生效时间段](#)。

----结束

后续处理

创建生效时间段后，还需创建ACL并配置与生效时间段关联的ACL规则。基本ACL的配置，请参见[5.7.1.3 配置基本ACL](#)。

配置小窍门

删除生效时间段

删除生效时间段前，需要先删除关联生效时间段的ACL规则或者整个ACL。

例如，在ACL 2001中配置了rule 5，该规则关联了时间段time1。

```
#
time-range time1 from 00:00 2014/1/1 to 23:59 2014/12/31
#
acl number 2001
 rule 5 permit time-range time1
#
```

如果需要删除时间段time1，则需先删除rule 5或者先删除ACL 2001。

- 先删除rule 5，再删除time1。

```
<Huawei> system-view
[Huawei] acl 2001
[Huawei-acl-basic-2001] undo rule 5
[Huawei-acl-basic-2001] quit
[Huawei] undo time-range time1
```

- 先删除ACL 2001，再删除time1。

```
<Huawei> system-view
[Huawei] undo acl 2001
[Huawei] undo time-range time1
```

相关资料

视频：[配置基于时间的ACL](#)

5.7.1.2 （可选）配置端口集

背景信息

配置TCP或UDP协议类型的高级ACL规则时，可以通过绑定端口集指定高级ACL规则匹配报文的源/目的端口号。在高级ACL规则匹配报文的源/目的端口号配置比较复杂，或多个ACL规则中需要定义相同的端口规则时，与在`rule`命令中通过参数`eq port`、`gt port`、`lt port`或`range port-start port-end`直接指定端口号相比，在`rule`命令中通过参数`port-set port-set-name`绑定端口集的配置方式更方便用户对高级ACL规则进行配置和维护。

操作步骤

- 步骤1** 执行命令`system-view`，进入系统视图。
- 步骤2** 执行命令`ip port-set port-set-name protocol { tcp | udp }`，创建端口集并进入端口集视图。
- 缺省情况下，设备没有创建端口集。
- 步骤3** 执行命令`port [ port-rule-id ] { eq port | gt port | lt port | range port-start port-end }`，配置端口集的端口规则。
- 缺省情况下，设备没有配置端口集的端口规则。
- 结束

后续处理

配置端口集后，还需创建高级ACL并配置与端口集关联的ACL规则。高级ACL的配置，请参见[5.7.2.2 配置高级ACL](#)。

5.7.1.3 配置基本 ACL

前提条件

如果配置基于时间的ACL，则需创建生效时间段，并将其与ACL规则关联起来。具体操作请参见[5.7.1.1 （可选）配置ACL的生效时间段](#)。

背景信息

基本ACL根据源IP地址、分片信息和生效时间段等信息来定义规则，对IPv4报文进行过滤。

如果只需要根据源IP地址对报文进行过滤，可以配置基本ACL。

操作步骤

- 步骤1** 执行命令`system-view`，进入系统视图。
- 步骤2** 创建基本ACL。可使用编号或者名称两种方式创建。
- 执行命令`acl [ number ] acl-number [ match-order { auto | config } ]`，使用编号（2000～2999）创建一个数字型的基本ACL，并进入基本ACL视图。

- 执行命令**acl name** *acl-name* { **basic** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的基本ACL，并进入基本ACL视图。

缺省情况下，未创建ACL。

关于数字型ACL和命名型ACL的详细介绍，请参见[5.2.2 ACL的分类](#)。

如果创建ACL时未指定**match-order**参数，则该ACL默认的规则匹配顺序为**config**。关于ACL匹配顺序的详细介绍，请参见[5.2.4 ACL的匹配顺序](#)。

创建ACL后，ACL的缺省步长为5。如果该值不能满足管理员部署ACL规则的需求，则可以对ACL步长值进行调整。关于步长的详细介绍，请参见[5.2.3 ACL的步长设定](#)；关于步长调整的具体操作，请参见[5.8.1 调整ACL规则的步长](#)。

如果要删除已生效的ACL，可参见[删除ACL](#)。

步骤3 （可选）执行命令**description** *text*，配置ACL的描述信息。

缺省情况下，未配置ACL的描述信息。

配置ACL时，为ACL添加描述信息可以方便理解和记忆该ACL的功能或具体用途。

步骤4 执行命令**rule** [*rule-id*] { **deny** | **permit** } [**source** { *source-address* *source-wildcard* | **any** } | **vpn-instance** *vpn-instance-name* | [**fragment** | **none-first-fragment**] | **logging** | **time-range** *time-name*] *，配置基本ACL的规则。

缺省情况下，未配置基本ACL规则。

以上步骤仅是一条permit/deny规则的配置步骤。实际配置ACL规则时，需根据具体的业务需求，决定配置多少条规则以及规则的先后匹配顺序。

关于生效时间段、源IP地址及其通配符掩码和IP分片信息的详细介绍，请参见[5.2.5 ACL的常用匹配项](#)。详细的规则配置示例，请参见[配置基本ACL规则](#)。

步骤5 （可选）执行命令**rule** *rule-id* **description** *description*，配置ACL规则的描述信息。

缺省情况下，各规则没有描述信息。

配置ACL规则时，为ACL规则添加描述信息，可以方便理解和记忆该ACL规则的功能或具体用途。

设备仅允许为已存在的规则添加描述信息，不允许先配置规则的描述信息再配置具体的规则内容。如果在设备上删除已经配置了描述信息的规则，那么该规则对应的描述信息也一并被删除。

----结束

配置小窍门

删除ACL

系统视图下执行命令**undo acl** { [**number**] *acl-number* | **all** }或**undo acl name** *acl-name*，可以直接删除ACL。

配置基本ACL规则

- **配置基于源IP地址（主机地址）过滤报文的规则**

在ACL 2001中配置规则，允许源IP地址是192.168.1.3主机地址的报文通过。

```
<Huawei> system-view
[Huawei] acl 2001
[Huawei-acl-basic-2001] rule permit source 192.168.1.3 0
```

- **配置基于源IP地址（网段地址）过滤报文的规则**

在ACL 2001中配置规则，仅允许源IP地址是192.168.1.3主机地址的报文通过，拒绝源IP地址是192.168.1.0/24网段其他地址的报文通过，并配置ACL描述信息为Permit only 192.168.1.3 through。

```
<Huawei> system-view
[Huawei] acl 2001
[Huawei-acl-basic-2001] rule permit source 192.168.1.3 0
[Huawei-acl-basic-2001] rule deny source 192.168.1.0 0.0.0.255
[Huawei-acl-basic-2001] description Permit only 192.168.1.3 through
```

- **配置基于时间的ACL规则**

创建时间段working-time（周一到周五每天8:00到18:00），并在名称为work-acl的ACL中配置规则，在working-time限定的时间范围内，拒绝源IP地址是192.168.1.0/24网段地址的报文通过。

```
<Huawei> system-view
[Huawei] time-range working-time 8:00 to 18:00 working-day
[Huawei] acl name work-acl basic
[Huawei-acl-basic-work-acl] rule deny source 192.168.1.0 0.0.0.255 time-range working-time
```

- **配置基于IP分片信息、源IP地址（网段地址）过滤报文的规则**

在ACL 2001中配置规则，拒绝源IP地址是192.168.1.0/24网段地址的非首片分片报文通过。

```
<Huawei> system-view
[Huawei] acl 2001
[Huawei-acl-basic-2001] rule deny source 192.168.1.0 0.0.0.255 none-first-fragment
```

5.7.1.4 应用基本 ACL

背景信息

配置完ACL后，必须在具体的业务模块中应用ACL，才能使ACL正常下发和生效。

最基本的ACL应用方式，是在简化流策略/流策略中应用ACL，使设备能够基于全局或接口下发ACL，实现对转发报文的过滤。此外，ACL还可以应用在Telnet、FTP、路由等模块。

操作步骤

步骤1 应用基本ACL。

基本ACL的常见应用方式，如[表5-15](#)所示。

表 5-15 应用基本 ACL

业务分类	应用场景	各业务模块的ACL应用方式
对转发的报文进行过滤	基于全局和接口，对转发的报文进行过滤，从而使设备能够进一步对过滤出的报文进行丢弃、修改优先级、重定向等处理。 例如，可以利用ACL，降低P2P下载、网络视频等消耗大量带宽的数据流的服务等级，在网络拥塞时优先丢弃这类流量，减少它们对其他重要流量的影响。	● 简化流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“基于ACL的简化流策略配置” ● 流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“MQC 配置” ● 包过滤防火墙：请参见《 AR300, AR700 配置指南-防火墙配置 》中的“6.7 配置包过滤防火墙”
对上送CPU处理的报文进行过滤	对上送CPU的报文进行必要的限制，可以避免CPU处理过多的协议报文造成占用率过高、性能下降。 例如，当发现某用户向设备发送大量的ARP攻击报文，造成设备CPU繁忙，引发系统中断时，可以在本机防攻击策略的黑名单中应用ACL，将该用户加入黑名单，使CPU丢弃该用户发送的报文。	黑名单：请参见“本机防攻击配置”中的“8.4.2 配置黑名单”

业务分类	应用场景	各业务模块的ACL应用方式
登录控制	对设备的登录权限进行控制，允许合法用户登录，拒绝非法用户登录，从而有效防止未经授权用户的非法接入，保证网络安全。	• Telnet：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置Telnet服务器功能” • FTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过FTP进行文件操作” • SFTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过SFTP进行文件操作” • TFTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置设备作为TFTP客户端访问其他设备的文件” • Web登录：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置Web网管参数” • SNMP：请参见《 AR300, AR700 配置指南-网络管理与监控 》中的“（可选）限制网管对设备的管理权限”（SNMPv1、SNMPv2c）和“（可选）限制网管对设备的管理权限”（SNMPv3）

业务分类	应用场景	各业务模块的ACL应用方式
路由过滤	ACL可以应用在各种动态路由协议中，对路由协议发布、接收的路由信息以及组播组进行过滤。 例如，可以将ACL和路由策略配合使用，禁止设备将某网段路由发给邻居路由器。	• BGP：请参见《 AR300, AR700 配置指南-IP单播路由 》中的“控制BGP路由信息的发布”和“控制BGP路由信息的接收” • IS-IS（ IPv4 ）：请参见《 AR300, AR700 配置指南-IP单播路由 》中的“配置IS-IS发布部分外部路由到IS-IS路由域”和“配置将部分IS-IS路由下发到IP路由表” • OSPF：请参见《 AR300, AR700 配置指南-IP单播路由 》中的“配置OSPF对接收的路由进行过滤”、“配置OSPF对发布的路由进行过滤”和“（ 可选 ）配置Helper端GR的会话参数” • RIP：请参见《 AR300, AR700 配置指南-IP单播路由 》中的“配置RIP引入外部路由信息”和“配置RIP对接收的路由进行过滤” • 组播：请参见《 AR300, AR700 配置指南-IP组播 》中的“配置根据源地址过滤IGMP报文”、“配置组播组过滤策略”、“（ 可选 ）配置接口加入的组播组范围”和“（ 可选 ）配置SSM组策略”

----结束

5.7.1.5 检查基本 ACL 配置结果

操作步骤

- 执行命令**display acl { acl-number | name acl-name | all }**，查看ACL的配置信息。

- 执行命令**display time-range { all | time-name }**，查看时间段信息。
- 结束

5.7.2 配置并应用高级 ACL

5.7.2.1 （可选）配置 ACL 的生效时间段

背景信息

请参见“配置并应用基本ACL”中的[5.7.1.1 （可选）配置ACL的生效时间段](#)。

5.7.2.2 配置高级 ACL

前提条件

- 如果配置基于时间的ACL，则需创建生效时间段，并将其与ACL规则关联起来。具体操作请参见[5.7.1.1 （可选）配置ACL的生效时间段](#)。

背景信息

高级ACL根据源IP地址、目的IP地址、IP协议类型、TCP源/目的端口、UDP源/目的端口号、分片信息和生效时间段等信息来定义规则，对IPv4报文进行过滤。

高级ACL比基本ACL提供了更准确、丰富、灵活的规则定义方法。例如，当希望同时根据源IP地址和目的IP地址对报文进行过滤时，则需要配置高级ACL。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 创建高级ACL。可使用编号或者名称两种方式创建。

- 执行命令**acl [number] acl-number [match-order { auto | config }]**，使用编号（3000 ~ 3999）创建一个数字型的高级ACL，并进入高级ACL视图。
- 执行命令**acl name acl-name { advance | acl-number } [match-order { auto | config }]**，使用名称创建一个命名型的高级ACL，进入高级ACL视图。

缺省情况下，未创建ACL。

关于数字型ACL和命名型ACL的详细介绍，请参见[5.2.2 ACL的分类](#)。

如果创建ACL时未指定**match-order**参数，则该ACL默认的规则匹配顺序为**config**。关于ACL匹配顺序的详细介绍，请参见[5.2.4 ACL的匹配顺序](#)。

创建ACL后，ACL的缺省步长为5。如果该值不能满足管理员部署ACL规则的需求，则可以对ACL步长值进行调整。关于步长的详细介绍，请参见[5.2.3 ACL的步长设定](#)；关于步长调整的具体操作，请参见[5.8.1 调整ACL规则的步长](#)。

如果要删除已生效的ACL，可参见“配置基本ACL”中的[删除ACL](#)，此处不再赘述。

步骤3 （可选）执行命令**description text**，配置ACL的描述信息。

缺省情况下，未配置ACL的描述信息。

配置ACL时，为ACL添加描述信息可以方便理解和记忆该ACL的功能或具体用途。

步骤4 配置高级ACL规则。

根据IP承载的协议类型不同，在设备上配置不同的高级ACL规则。对于不同的协议类型，有不同的参数组合。

- 当IP承载的协议类型为ICMP时，高级访问控制列表的命令格式为：
rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **icmp** } [**destination** { *destination-address destination-wildcard* | **any** } | **icmp-type** { *icmp-name* | *icmp-type icmp-code* } | **source** { *source-address source-wildcard* | **any** } | **logging** | **time-range** *time-name* | **vpn-instance** *vpn-instance-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | [**fragment** | **none-first-fragment**] | **vni** *vni-id*] *
- 当IP承载的协议类型为TCP时，高级访问控制列表的命令格式为：
rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **tcp** } [**destination** { *destination-address destination-wildcard* | **any** } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* | **port-set** *port-set-name* } | **source** { *source-address source-wildcard* | **any** } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* | **port-set** *port-set-name* } | **tcp-flag** { **ack** | **fin** | **psh** | **rst** | **syn** | **urg** | **established** } * | **logging** | **time-range** *time-name* | **vpn-instance** *vpn-instance-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | [**fragment** | **none-first-fragment**] | **vni** *vni-id*] *
- 当IP承载的协议类型为UDP时，高级访问控制列表的命令格式为：
rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **udp** } [**destination** { *destination-address destination-wildcard* | **any** } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* | **port-set** *port-set-name* } | **source** { *source-address source-wildcard* | **any** } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* | **port-set** *port-set-name* } | **logging** | **time-range** *time-name* | **vpn-instance** *vpn-instance-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | [**fragment** | **none-first-fragment**] | **vni** *vni-id*] *
- 当IP承载的协议类型为GRE、IGMP、IP、IPINIP、OSPF时，高级访问控制列表的命令格式为：
rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **gre** | **igmp** | **ip** | **ipinip** | **ospf** } [**destination** { *destination-address destination-wildcard* | **any** } | **source** { *source-address source-wildcard* | **any** } | **logging** | **time-range** *time-name* | **vpn-instance** *vpn-instance-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | [**fragment** | **none-first-fragment**] | **vni** *vni-id*] *

说明

如果要同时配置 **precedence** *precedence* 和 **tos** *tos* 参数，则需将 **precedence** *precedence* 和 **tos** *tos* 参数连续配置。

参数 **dscp** *dscp* 和 **precedence** *precedence* 不能同时配置。

参数 **dscp** *dscp* 和 **tos** *tos* 不能同时配置。

仅在 VXLAN 场景下配置参数 **vni** *vni-id* 才有效。

在 ACL 中配置首条规则时，如果未指定参数 **rule-id**，设备使用步长值作为规则的起始编号。后续配置规则如仍未指定参数 **rule-id**，设备则使用最后一个规则的 **rule-id** 的下一个步长的整数倍数值作为规则编号。例如 ACL 中包含规则 rule 5 和 rule 7，ACL 的步长为 5，则系统分配给新配置的未指定 **rule-id** 的规则编号为 10。

当用户指定参数 **time-range** 引入 ACL 规则生效时间段时，如果 **time-name** 不存在，则该规则配置不生效。

步骤5 （可选）执行命令 **rule rule-id description description**，配置 ACL 规则的描述信息。

缺省情况下，各规则没有描述信息。

配置 ACL 规则时，为 ACL 规则添加描述信息，可以方便理解和记忆该 ACL 规则的功能或具体用途。

设备仅允许为已存在的规则添加描述信息，不允许先配置规则的描述信息再配置具体的规则内容。如果在设备上删除已经配置了描述信息的规则，那么该规则对应的描述信息也一并被删除。

----结束

配置小窍门

配置高级 ACL 规则

- 配置基于 ICMP 协议类型、源 IP 地址（主机地址）和目的 IP 地址（网段地址）过滤报文的规则

在 ACL 3001 中配置规则，允许源 IP 地址是 192.168.1.3 主机地址且目的 IP 地址是 192.168.2.0/24 网段地址的 ICMP 报文通过。

```
<Huawei> system-view
[Huawei] acl 3001
[Huawei-acl-adv-3001] rule permit icmp source 192.168.1.3 0 destination 192.168.2.0 0.0.0.255
```

- 配置基于 TCP 协议类型、TCP 目的端口号、源 IP 地址（主机地址）和目的 IP 地址（网段地址）过滤报文的规则

在名称为 deny-telnet 的高级 ACL 中配置规则，拒绝 IP 地址是 192.168.1.3 的主机与 192.168.2.0/24 网段的主机建立 Telnet 连接。

```
<Huawei> system-view
[Huawei] acl name deny-telnet
[Huawei-acl-adv-deny-telnet] rule deny tcp destination-port eq telnet source 192.168.1.3 0
destination 192.168.2.0 0.0.0.255
```

在名称为 no-web 的高级 ACL 中配置规则，禁止 192.168.1.3 和 192.168.1.4 两台主机访问 Web 网页（HTTP 协议用于网页浏览，对应 TCP 端口号是 80），并配置 ACL 描述信息为 Web access restrictions。

```
<Huawei> system-view
[Huawei] acl name no-web
[Huawei-acl-adv-no-web] description Web access restrictions
[Huawei-acl-adv-no-web] rule deny tcp destination-port eq 80 source 192.168.1.3 0
[Huawei-acl-adv-no-web] rule deny tcp destination-port eq 80 source 192.168.1.4 0
```

- 配置基于 TCP 协议类型、源 IP 地址（网段地址）和 TCP 标志信息过滤报文的规则

在 ACL 3002 中配置规则，拒绝 192.168.2.0/24 网段的主机主动发起的 TCP 握手报文通过，允许该网段主机被动响应 TCP 握手的报文通过，实现 192.168.2.0/24 网段地

址的单向访问控制。同时，配置ACL规则描述信息分别为Allow the ACK TCP packets through、Allow the RST TCP packets through和Do not Allow the other TCP packet through。

完成以上配置，必须先配置两条permit规则，允许192.168.2.0/24网段的ACK=1或RST=1的报文通过，再配置一条deny规则，拒绝该网段的其他TCP报文通过。

```
<Huawei> system-view
[Huawei] acl 3002
[Huawei-acl-adv-3002] rule permit tcp source 192.168.2.0 0.0.0.255 tcp-flag ack
[Huawei-acl-adv-3002] display this //如果配置规则时未指定规则编号，则可以通过此步骤查看到系统
为该规则分配的编号，然后根据该编号，为该规则配置描述信息。
#
acl number 3002
rule 5 permit tcp source 192.168.2.0 0.0.0.255 tcp-flag ack //系统分配的规则编号是5
#
return
[Huawei-acl-adv-3002] rule 5 description Allow the ACK TCP packets through
[Huawei-acl-adv-3002] rule permit tcp source 192.168.2.0 0.0.0.255 tcp-flag rst
[Huawei-acl-adv-3002] display this
#
acl number 3002
rule 5 permit tcp source 192.168.2.0 0.0.0.255 tcp-flag ack syn
rule 5 description Allow the ACK TCP packets through
rule 10 deny tcp source 192.168.2.0 0.0.0.255 tcp-flag rst //系统分配的规则编号是10
#
return
[Huawei-acl-adv-3002] rule 10 description Allow the RST TCP packets through
[Huawei-acl-adv-3002] rule deny tcp source 192.168.2.0 0.0.0.255
[Huawei-acl-adv-3002] display this
#
acl number 3002
rule 5 permit tcp source 192.168.2.0 0.0.0.255 tcp-flag ack syn
rule 5 description Allow the ACK TCP packets through
rule 10 deny tcp source 192.168.2.0 0.0.0.255 tcp-flag rst
rule 10 description Allow the RST TCP packets through
rule 15 deny tcp source 192.168.2.0 0.0.0.255 //系统分配的规则编号是15
#
return
[Huawei-acl-adv-3002] rule 15 description Do not Allow the other TCP packet through
```

- **配置基于时间的ACL规则**

请参见“配置基本ACL”中的[配置基于时间的ACL规则](#)，不再赘述。

- **配置基于IP分片信息、源IP地址（网段地址）过滤报文的规则**

请参见“配置基本ACL”中的[配置基于IP分片信息、源IP地址（网段地址）过滤报文的规则](#)，不再赘述。

5.7.2.3 应用高级 ACL

背景信息

配置完ACL后，必须在具体的业务模块中应用ACL，才能使ACL正常下发和生效。

最基本的ACL应用方式，是在简化流策略/流策略中应用ACL，使设备能够基于全局或接口下发ACL，实现对转发报文的过滤。此外，ACL还可以应用在FTP、组播等模块。

操作步骤

步骤1 应用高级ACL。

高级ACL的常见应用方式，如[表5-16](#)所示。

表 5-16 应用高级 ACL

业务分类	应用场景	各业务模块的ACL应用方式
对转发的报文进行过滤	基于全局和接口，对转发的报文进行过滤，从而使设备能够进一步对过滤出的报文进行丢弃、修改优先级、重定向等处理。 例如，可以利用ACL，降低P2P下载、网络视频等消耗大量带宽的数据流的服务等级，在网络拥塞时优先丢弃这类流量，减少它们对其他重要流量的影响。	● 简化流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“基于ACL的简化流策略配置” ● 流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“MQC 配置” ● 包过滤防火墙：请参见《 AR300, AR700 配置指南-防火墙配置 》中的“6.7 配置包过滤防火墙”
对上送CPU处理的报文进行过滤	对上送CPU的报文进行必要的限制，可以避免CPU处理过多的协议报文造成占用率过高、性能下降。 例如，当发现某用户向设备发送大量的ARP攻击报文，造成设备CPU繁忙，引发系统中断时，可以在本机防攻击策略的黑名单中应用ACL，将该用户加入黑名单，使CPU丢弃该用户发送的报文。	黑名单：请参见“本机防攻击配置”中的“8.4.2 配置黑名单”
登录控制	对设备的登录权限进行控制，允许合法用户登录，拒绝非法用户登录，从而有效防止未经授权用户的非法接入，保证网络安全。	● Telnet：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置Telnet服务器功能” ● FTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过FTP进行文件操作” ● SFTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过SFTP进行文件操作”

业务分类	应用场景	各业务模块的ACL应用方式
路由过滤	ACL可以应用在组播协议中，实现组播组的过滤。 例如，可以将ACL和IGMP Snooping配合使用，禁止VLAN内的主机加入指定组播组。	组播：请参见《 AR300, AR700 配置指南-IP组播 》中的“配置组播组过滤策略”、“配置根据源地址过滤IGMP报文”和“（可选）配置接口加入的组播组范围”

----结束

5.7.2.4 检查高级 ACL 配置结果

操作步骤

- 执行命令**display acl { acl-number | name acl-name | all }**，查看ACL的配置信息。
- 执行命令**display time-range { all | time-name }**，查看时间段信息。

----结束

5.7.3 配置并应用二层 ACL

5.7.3.1 （可选）配置 ACL 的生效时间段

背景信息

请参见“配置并应用基本ACL”中的[5.7.1.1 （可选）配置ACL的生效时间段](#)。

5.7.3.2 配置二层 ACL

前提条件

如果配置基于时间的ACL，则需创建生效时间段，并将其与ACL规则关联起来。具体操作请参见[5.7.1.1 （可选）配置ACL的生效时间段](#)。

背景信息

二层ACL根据以太网帧头信息来定义规则，如源MAC（Media Access Control）地址、目的MAC地址、VLAN、二层协议类型等，对IPv4和IPv6报文进行过滤。

如果只需要根据二层信息过滤报文，可以配置二层ACL。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 创建二层ACL。可使用编号或者名称两种方式创建。

- 执行命令**acl [number] acl-number [match-order { auto | config }]**，使用编号（4000～4999）创建一个数字型的二层ACL，并进入二层ACL视图。
- 执行命令**acl name acl-name { link | acl-number } [match-order { auto | config }]**，使用名称创建一个命名型的二层ACL，进入二层ACL视图。

缺省情况下，未创建ACL。

关于数字型ACL和命名型ACL的详细介绍，请参见[5.2.2 ACL的分类](#)。

如果创建ACL时未指定**match-order**参数，则该ACL默认的规则匹配顺序为**config**。关于ACL匹配顺序的详细介绍，请参见[5.2.4 ACL的匹配顺序](#)。

创建ACL后，ACL的缺省步长为5。如果该值不能满足管理员部署ACL规则的需求，则可以对ACL步长值进行调整。关于步长的详细介绍，请参见[5.2.3 ACL的步长设定](#)；关于步长调整的具体操作，请参见[5.8.1 调整ACL规则的步长](#)。

如果要删除已生效的ACL，可参见“配置基本ACL”中的[删除ACL](#)，此处不再赘述。

步骤3 （可选）执行命令**description text**，配置ACL的描述信息。

缺省情况下，未配置ACL的描述信息。

配置ACL时，为ACL添加描述信息可以方便理解和记忆该ACL的功能或具体用途。

步骤4 执行命令**rule [rule-id] { permit | deny } [l2-protocol type-value [type-mask] | destination-mac dest-mac-address [dest-mac-mask] | source-mac source-mac-address [source-mac-mask] | vlan-id vlan-id [vlan-id-mask] | 8021p 802.1p-value | time-range time-name] ***，配置二层ACL的规则。

以上步骤仅是一条permit/deny规则的配置步骤。实际配置ACL规则时，需根据具体的业务需求，决定配置多少条规则以及规则的先后匹配顺序。

关于生效时间段、源/目的MAC地址及其通配符掩码、VLAN编号及其掩码的详细介绍，请参见[5.2.5 ACL的常用匹配项](#)。详细的规则配置示例，请参见[配置二层ACL规则](#)。

步骤5 （可选）执行命令**rule rule-id description description**，配置ACL规则的描述信息。

缺省情况下，各规则没有描述信息。

配置ACL规则时，为ACL规则添加描述信息，可以方便理解和记忆该ACL规则的功能或具体用途。

设备仅允许为已存在的规则添加描述信息，不允许先配置规则的描述信息再配置具体的规则内容。如果在设备上删除已经配置了描述信息的规则，那么该规则对应的描述信息也一并被删除。

----结束

配置小窍门

配置二层ACL规则

- **配置基于源MAC地址（单个MAC地址）、目的MAC地址（单个MAC地址）和二层协议类型过滤报文的规则**

在ACL 4001中配置规则，允许目的MAC地址是00e0-fc01-0101、源MAC地址是00e0-fc01-0102的ARP报文（二层协议类型值为0x0806）通过。

```
<Huawei> system-view
[Huawei] acl 4001
[Huawei-acl-L2-4001] rule permit destination-mac 00e0-fc01-0101 source-mac 00e0-fc01-0102 l2-protocol 0x0806
```

在ACL 4001中配置规则，拒绝PPPoE报文（二层协议类型值为0x8863）通过。

```
<Huawei> system-view
[Huawei] acl 4001
[Huawei-acl-L2-4001] rule deny l2-protocol 0x8863
```

- **配置基于源MAC地址（MAC地址段）和内层VLAN过滤报文的规则**

在名称为deny-vlan10-mac的二层ACL中配置规则，拒绝来自VLAN10且源MAC地址在00e0-fc01-0000～00e0-fc01-ffff范围内的报文通过。

```
<Huawei> system-view
[Huawei] acl name deny-vlan10-mac link
[Huawei-acl-L2-deny-vlan10-mac] rule deny vlan-id 10 source-mac 00e0-fc01-0000 ffff-ffff-0000
```

- **配置基于时间的ACL规则**

请参见“配置基本ACL”中的[配置基于时间的ACL规则](#)，不再赘述。

5.7.3.3 应用二层 ACL

背景信息

配置完ACL后，必须在具体的业务模块中应用ACL，才能使ACL正常下发和生效。

最基本的ACL应用方式，是在简化流策略/流策略中应用ACL，使设备能够基于全局或接口下发ACL，实现对转发报文的过滤。此外，ACL还可以应用在本机防攻击等模块。

操作步骤

步骤1 应用二层ACL。

二层ACL的常见应用方式，如[表5-17](#)所示。

表 5-17 应用二层 ACL

业务分类	应用场景	各业务模块的ACL应用方式
对转发的报文进行过滤	基于全局和接口，对转发的报文进行过滤，从而使设备能够进一步对过滤出的报文进行丢弃、修改优先级、重定向等处理。 例如，可以利用ACL，降低P2P下载、网络视频等消耗大量带宽的数据流的服务等级，在网络拥塞时优先丢弃这类流量，减少它们对其他重要流量的影响。	• 简化流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“基于ACL的简化流策略配置” • 流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“MQC 配置” • 包过滤防火墙：请参见《 AR300, AR700 配置指南-防火墙配置 》中的“6.7 配置包过滤防火墙”
对上送CPU处理的报文进行过滤	对上送CPU的报文进行必要的限制，可以避免CPU处理过多的协议报文造成占用率过高、性能下降。 例如，当发现某用户向设备发送大量的ARP攻击报文，造成设备CPU繁忙，引发系统中断时，可以在本机防攻击策略的黑名单中应用ACL，将该用户加入黑名单，使CPU丢弃该用户发送的报文。	黑名单：请参见“本机防攻击配置”中的“8.4.2 配置黑名单”

----结束

5.7.3.4 检查二层 ACL 配置结果

操作步骤

- 执行命令**display acl { acl-number | name acl-name | all }**，查看ACL的配置信息。
- 执行命令**display time-range { all | time-name }**，查看时间段信息。

----结束

5.7.4 配置并应用用户 ACL

5.7.4.1 （可选）配置 ACL 的生效时间段

背景信息

请参见“配置并应用基本ACL”中的[5.7.1.1（可选）配置ACL的生效时间段](#)。

5.7.4.2 配置用户 ACL

背景信息

用户ACL根据IPv4报文的源IP地址、目的IP地址、IP协议类型、ICMP类型、TCP源端口/目的端口、UDP源端口/目的端口号、生效时间段等来定义规则，对IPv4报文进行过滤。

如果需要配置Portal用户的免认证规则，可以配置用户ACL。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 创建用户ACL。仅支持使用编号创建。

- 执行命令**acl [number] acl-number [match-order { auto | config }]**，使用编号（6000～6031）创建一个数字型的用户ACL，并进入用户ACL视图。

缺省情况下，未创建ACL。

关于数字型ACL和命名型ACL的详细介绍，请参见[5.2.2 ACL的分类](#)。

如果创建ACL时未指定**match-order**参数，则该ACL默认的规则匹配顺序为**config**。关于ACL匹配顺序的详细介绍，请参见[5.2.4 ACL的匹配顺序](#)。

创建ACL后，ACL的缺省步长为5。如果该值不能满足管理员部署ACL规则的需求，则可以对ACL步长值进行调整。关于步长的详细介绍，请参见[5.2.3 ACL的步长设定](#)；关于步长调整的具体操作，请参见[5.8.1 调整ACL规则的步长](#)。

如果要删除已生效的ACL，可参见“配置基本ACL”中的[删除ACL](#)，此处不再赘述。

步骤3 （可选）执行命令**description text**，配置ACL的描述信息。

缺省情况下，未配置ACL的描述信息。

配置ACL时，为ACL添加描述信息可以方便理解和记忆该ACL的功能或具体用途。

步骤4 配置用户ACL规则。

根据IP承载的协议类型不同，在设备上配置不同的用户ACL规则。对于不同的协议类型，有不同的参数组合。

- 当参数protocol为ICMP时，用户访问控制列表的命令格式为：
rule [rule-id] { deny | permit } { protocol-number | icmp } [destination { destination-address destination-wildcard | any | passthrough-domain domain-string } | icmp-type { icmp-name | icmp-type icmp-code } | source { source-address source-wildcard | any } | time-range time-name | [dscp dscp | [tos tos | precedence precedence] *] | fragment] *
- 当参数protocol为TCP时，用户访问控制列表的命令格式为：
rule [rule-id] { deny | permit } { protocol-number | tcp } [destination { destination-address destination-wildcard | any | passthrough-domain


```
domain-string } | destination-port { eq port | gt port | lt port | range port-start port-end } | source { source-address source-wildcard | any } | source-port { eq port | gt port | lt port | range port-start port-end } | tcp-flag { ack | fin | psh | rst | syn | urg } * | time-range time-name | [ dscp dscp | [ tos tos | precedence precedence ] * ] | fragment ] *
```

- 当参数protocol为UDP时，用户访问控制列表的命令格式为：

```
rule [ rule-id ] { deny | permit } { protocol-number | udp } [ destination { destination-address destination-wildcard | any | passthrough-domain domain-string } | destination-port { eq port | gt port | lt port | range port-start port-end } | source { source-address source-wildcard | any } | source-port { eq port | gt port | lt port | range port-start port-end } | time-range time-name | [ dscp dscp | [ tos tos | precedence precedence ] * ] | fragment ] *
```

- 当参数protocol为GRE、IGMP、IP、IPINIP、OSPF时，用户访问控制列表的命令格式为：

```
rule [ rule-id ] { deny | permit } { protocol-number | gre | igmp | ip | ipinip | ospf } [ destination { destination-address destination-wildcard | any | passthrough-domain domain-string } | source { source-address source-wildcard | any } | time-range time-name | [ dscp dscp | [ tos tos | precedence precedence ] * ] | fragment ] *
```

以上步骤仅是一条permit/deny规则的配置步骤。实际配置ACL规则时，需根据具体的业务需求，决定配置多少条规则以及规则的先后匹配顺序。

详细的规则配置示例，请参见[配置用户ACL规则](#)。

步骤5 （可选）执行命令**rule rule-id description description**，配置ACL规则的描述信息。

缺省情况下，各规则没有描述信息。

配置ACL规则时，为ACL规则添加描述信息，可以方便理解和记忆该ACL规则的功能或具体用途。

设备仅允许为已存在的规则添加描述信息，不允许先配置规则的描述信息再配置具体的规则内容。如果在设备上删除已经配置了描述信息的规则，那么该规则对应的描述信息也一并被删除。

----结束

配置小窍门

配置用户ACL规则

- 配置基于目的IP地址过滤报文的规则**

在ACL 6000中配置规则，允许所有Portal用户可以免认证访问IP地址为10.1.1.1/24的网络。

```
<Huawei> system-view  
[Huawei] acl 6000  
[Huawei-acl-ucl-6000] rule permit ip destination 10.1.1.1 255.255.255.0
```

- 配置基于时间的ACL规则**

请参见“配置基本ACL”中的[配置基于时间的ACL规则](#)，不再赘述。

5.7.4.3 应用用户 ACL

背景信息

配置完ACL后，必须在具体的业务模块中应用ACL，才能使ACL正常下发和生效。

目前用户ACL仅支持在NAC特性的Portal认证中应用。通过配置Portal认证，并配置用户ACL关联Portal认证用户的免认证规则可使特定的用户不经过认证或认证失败的情况下能够访问特定的网络资源。

操作步骤

步骤1 应用用户ACL。

用户ACL的应用方式，如[表5-18](#)所示。

表 5-18 应用用户 ACL

业务分类	应用场景	各业务模块的ACL应用方式
对转发的报文进行过滤	将用户ACL与Portal认证用户的免认证规则绑定，可使特定的用户不经过认证或认证失败的情况下能够访问特定的网络资源。	NAC：请参见 3.5.3.4（可选）配置用户的免认证授权信息

----结束

5.7.4.4 检查用户 ACL 配置结果

操作步骤

- 执行命令**display acl { acl-number | name acl-name | all }**，查看ACL的配置信息。
- 执行命令**display time-range { all | time-name }**，查看时间段信息。

----结束

5.7.5 配置并应用基本 ACL6

5.7.5.1 （可选）配置 ACL6 的生效时间段

背景信息

ACL6与ACL关联的生效时间段相同，配置方法请参见“配置并应用基本ACL”中的[5.7.1.1（可选）配置ACL的生效时间段](#)。

5.7.5.2 配置基本 ACL6

前提条件

如果配置基于时间的ACL6，则需创建生效时间段，并将其与ACL6规则关联起来。具体操作请参见[5.7.5.1（可选）配置ACL6的生效时间段](#)。

背景信息

基本ACL6根据源IPv6地址、分片信息和生效时间段等信息来定义规则，对IPv6报文进行过滤。

如果只需要根据源IPv6地址对报文进行过滤，可以配置基本ACL6。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 创建基本ACL6。可使用编号或者名称两种方式创建。

- 执行命令**acl ipv6 [number] acl6-number [match-order { auto | config }]**，使用编号（2000～2999）创建一个数字型的基本ACL6，并进入基本ACL6视图。
- 执行命令**acl ipv6 name acl6-name { basic | acl6-number } [match-order { auto | config }]**，使用名称创建一个命名型的基本ACL6，并进入基本ACL6视图。

缺省情况下，未创建ACL6。

数字型ACL6和命名型ACL6的原理同数字型ACL和命名型ACL，详细介绍请参见[5.2.2 ACL的分类](#)。

如果创建ACL6时未指定**match-order**参数，则该ACL6默认的规则匹配顺序为**config**。ACL6的规则匹配顺序同ACL匹配顺序，详细介绍请参见[5.2.4 ACL的匹配顺序](#)。

如果要删除已生效的ACL6，可参见[删除ACL6](#)。

步骤3 执行命令**rule [rule-id] { deny | permit } [[fragment | none-first-fragment] | source { source-ipv6-address prefix-length | source-ipv6-address/prefix-length | any } | logging | time-range time-name] ***，配置基本ACL6规则。

以上步骤仅是一条permit/deny规则的配置步骤。实际配置ACL规则时，需根据具体的业务需求，决定配置多少条规则以及规则的先后匹配顺序。

详细的规则配置示例，请参见[配置基本ACL6规则](#)。

步骤4 （可选）执行命令**rule rule-id description description**，配置ACL规则的描述信息。

缺省情况下，各规则没有描述信息。

配置ACL规则时，为ACL规则添加描述信息，可以方便理解和记忆该ACL规则的功能或具体用途。

设备仅允许为已存在的规则添加描述信息，不允许先配置规则的描述信息再配置具体的规则内容。如果在设备上删除已经配置了描述信息的规则，那么该规则对应的描述信息也一并被删除。

----结束

配置小窍门

删除ACL6

系统视图下执行命令`undo acl ipv6 { all | [ number ] acl6-number }`或`undo acl ipv6 name acl6-name`，可以直接删除ACL6。

配置基本ACL6规则

- 配置基于源IPv6地址（主机地址）过滤报文的规则

在ACL6 2001中配置规则，允许源IPv6地址是fc00:1::1/128主机地址的报文通过。

```
<Huawei> system-view
[Huawei] acl ipv6 2001
[Huawei-acl6-basic-2001] rule permit source fc00:1::1 128
```

- 配置基于源IPv6地址（网段地址）过滤报文的规则

在ACL6 2001中配置规则，仅允许源IPv6地址是fc00:1::1/128主机地址的报文通过，拒绝源IPv6地址是fc00:1::/64网段其他地址的报文通过。

```
<Huawei> system-view
[Huawei] acl ipv6 2001
[Huawei-acl6-basic-2001] rule permit source fc00:1::1 128
[Huawei-acl6-basic-2001] rule deny source fc00:1:: 64
```

- 配置基于时间的ACL6规则

请参见“配置基本ACL”中的[配置基于时间的ACL规则](#)，不再赘述。

- 配置基于IP分片信息、源IP地址（网段地址）过滤报文的规则

请参见“配置基本ACL”中的[配置基于IP分片信息、源IP地址（网段地址）过滤报文的规则](#)，不再赘述。

5.7.5.3 应用基本 ACL6

背景信息

配置完ACL6后，必须在具体的业务模块中应用ACL6，才能使ACL6正常下发和生效。

最基本的ACL6应用方式，是在简化流策略/流策略中应用ACL6，使设备能够基于全局或接口下发ACL6，实现对转发报文的过滤。此外，ACL6还可以应用在Telnet、FTP、路由等模块。

操作步骤

步骤1 应用基本ACL6。

基本ACL的常见应用方式，如[表5-19](#)所示。

表 5-19 应用基本 ACL6

业务分类	应用场景	各业务模块的ACL应用方式
对转发的报文进行过滤	基于全局和接口，对转发的报文进行过滤，从而使设备能够进一步对过滤出的报文进行丢弃、修改优先级、重定向等处理。 例如，可以利用ACL6，降低P2P下载、网络视频等消耗大量带宽的数据流的服务等级，在网络拥塞时优先丢弃这类流量，减少它们对其他重要流量的影响。	● 简化流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“基于ACL的简化流策略配置” ● 流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“MQC配置” ● 包过滤防火墙：请参见《 AR300, AR700 配置指南-防火墙配置 》中的“6.7 配置包过滤防火墙”
登录控制	对设备的登录权限进行控制，允许合法用户登录，拒绝非法用户登录，从而有效防止未经授权用户的非法接入，保证网络安全。 例如，一般情况下设备只允许管理员登录，非管理员用户不允许随意登录。这时就可以在Telnet中应用ACL6，并在ACL6中定义哪些主机可以登录，哪些主机不能。	● Telnet：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置Telnet服务器功能” ● FTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过FTP进行文件操作” ● SFTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过SFTP进行文件操作” ● SNMP：请参见《 AR300, AR700 配置指南-网络管理与监控 》中的“（可选）限制网管对设备的管理权限”（SNMPv1、SNMPv2c）和“（可选）限制网管对设备的管理权限”（SNMPv3）

业务分类	应用场景	各业务模块的ACL应用方式
路由过滤	ACL可以应用在各种动态路由协议中，对路由协议发布、接收的路由信息以及组播组进行过滤。 例如，可以将ACL和路由策略配合使用，禁止设备将某网段路由发给邻居路由器。	- IS-IS（IPv6）：请参见《AR300, AR700 配置指南-IP单播路由》中的“配置IS-IS发布部分外部路由到IS-IS路由域”和“配置将部分IS-IS路由下发到IP路由表” - OSPFv3：请参见《AR300, AR700 配置指南-IP单播路由》中的“配置OSPFv3对接收的路由进行过滤”、“配置OSPFv3引入外部路由”和“使能OSPFv3 GR的Helper能力” - RIPng：请参见《AR300, AR700 配置指南-IP单播路由》中的“配置RIPng引入外部路由”和“控制RIPng路由信息的接收” - 组播：请参见《AR300, AR700 配置指南-IP组播》中的“配置根据源地址过滤IGMP报文”、“配置组播组过滤策略”、“（可选）配置接口加入的组播组范围”和“（可选）配置SSM组策略”

----结束

5.7.5.4 检查基本 ACL6 配置结果

操作步骤

- 执行命令**display acl ipv6 { acl6-number | name acl6-name | all }**，查看ACL6的配置信息。
- 执行命令**display time-range { all | time-name }**，查看时间段信息。

----结束

5.7.6 配置并应用高级 ACL6

5.7.6.1 （可选）配置 ACL6 的生效时间段

背景信息

ACL6与ACL关联的生效时间段相同，配置方法请参见“配置并应用基本ACL”中的[5.7.1.1（可选）配置ACL的生效时间段](#)。

5.7.6.2 配置高级 ACL6

前提条件

如果配置基于时间的ACL6，则需创建生效时间段，并将其与ACL6规则关联起来。具体操作请参见[5.7.5.1（可选）配置ACL6的生效时间段](#)。

背景信息

高级ACL6根据源IPv6地址、目的IPv6地址、IPv6协议类型、TCP源/目的端口号、UDP源/目的端口号、分片信息和生效时间段等信息来定义规则，对IPv6报文进行过滤。

高级ACL6比基本ACL6提供了更准确、丰富、灵活的规则定义方法。例如，当希望同时根据源IPv6地址和目的IPv6地址对报文进行过滤时，则需要配置高级ACL6。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 创建高级ACL。可使用编号或者名称两种方式创建。

- 执行命令**acl ipv6 [number] acl6-number [match-order { auto | config }]**，使用编号（3000 ~ 3999）创建一个数字型的高级ACL6，并进入高级ACL6视图。
- 执行命令**acl ipv6 name acl6-name { advance | acl6-number } [match-order { auto | config }]**，使用名称创建一个命名型的高级ACL6，进入高级ACL6视图。

缺省情况下，未创建ACL。

数字型ACL6和命名型ACL6的原理同数字型ACL和命名型ACL，详细介绍请参见[5.2.2 ACL的分类](#)。

如果创建ACL6时未指定**match-order**参数，则该ACL6默认的规则匹配顺序为**config**。ACL6的规则匹配顺序同ACL匹配顺序，详细介绍请参见[5.2.4 ACL的匹配顺序](#)。

如果要删除已生效的ACL，可参见“配置基本ACL6”中的[删除ACL](#)，此处不再赘述。

步骤3 配置高级ACL6规则。

根据IP承载的协议类型不同，在设备上配置不同的高级ACL6规则。对于不同的协议类型，有不同的参数组合。

- 当参数protocol为TCP时，高级ACL6的命令格式为：
rule [rule-id] { deny | permit } { protocol-number | tcp } [destination { [pd prefix] destination-ipv6-address prefix-length | [pd prefix] destination-ipv6-address/prefix-length | any | pd destination-dhcpv6-prefix } | destination-port { eq port | gt port | lt port | range port-start port-end } | dscp dscp | precedence precedence | source { [pd prefix] source-ipv6-address prefix-length | [pd prefix] source-ipv6-address/prefix-length | any | pd source-dhcpv6-prefix } | source-port { eq port | gt port | lt port | range port-start port-end } | tcp-flag { ack | fin | psh | rst | syn | urg | established } * | logging | time-range time-name | tos tos] *
- 当参数protocol为UDP时，高级ACL6的命令格式为：


```
rule [ rule-id ] { deny | permit } { protocol-number | udp } [ destination  
{ [ pd prefix ] destination-ipv6-address prefix-length | [ pd prefix ]  
destination-ipv6-address/prefix-length | any | pd destination-dhcpv6-prefix } |  
destination-port { eq port | gt port | lt port | range port-start port-end } |  
dscp dscp | precedence precedence | source { [ pd prefix ] source-ipv6-  
address prefix-length | [ pd prefix ] source-ipv6-address/prefix-length | any |  
pd source-dhcpv6-prefix } | source-port { eq port | gt port | lt port | range  
port-start port-end } | logging | time-range time-name | tos tos ] *
```

- 当参数protocol为ICMPv6时，高级ACL6的命令格式为：

```
rule [ rule-id ] { deny | permit } { protocol-number | icmpv6 } [ destination  
{ destination-ipv6-address prefix-length | destination-ipv6-address/prefix-  
length | any } | dscp dscp | icmp6-type { icmp6-type-name | icmp6-type  
icmp6-code } | precedence precedence | source { source-ipv6-address prefix-  
length | source-ipv6-address/prefix-length | any } | logging | time-range  
time-name | tos tos ] *
```

- 当protocol为IPv6时，高级ACL6的命令格式为：

```
rule [ rule-id ] { deny | permit } { protocol-number | ipv6 } [ destination  
{ [ pd prefix ] destination-ipv6-address prefix-length | [ pd prefix ]  
destination-ipv6-address/prefix-length | any | pd destination-dhcpv6-prefix } |  
dscp dscp | [ fragment | none-first-fragment ] | precedence precedence |  
source { [ pd prefix ] source-ipv6-address prefix-length | [ pd prefix ] source-  
ipv6-address/prefix-length | any | pd source-dhcpv6-prefix } | logging | time-  
range time-name | tos tos ] *
```

- 当protocol为其他协议时，高级ACL6的命令格式为：

```
rule [ rule-id ] { deny | permit } { protocol-number | gre | ospf }  
[ destination { destination-ipv6-address prefix-length | destination-ipv6-  
address/prefix-length | any } | dscp dscp | precedence precedence | source  
{ source-ipv6-address prefix-length | source-ipv6-address/prefix-length | any }  
| logging | time-range time-name | tos tos ] *
```

以上步骤仅是一条permit/deny规则的配置步骤。实际配置ACL规则时，需根据具体的业务需求，决定配置多少条规则以及规则的先后匹配顺序。

详细的规则配置示例，请参见[配置高级ACL6规则](#)。

步骤4 （可选）执行命令**rule rule-id description description**，配置ACL规则的描述信息。

缺省情况下，各规则没有描述信息。

配置ACL规则时，为ACL规则添加描述信息，可以方便理解和记忆该ACL规则的功能或具体用途。

设备仅允许为已存在的规则添加描述信息，不允许先配置规则的描述信息再配置具体的规则内容。如果在设备上删除已经配置了描述信息的规则，那么该规则对应的描述信息也一并被删除。

----结束

配置小窍门

配置高级ACL6规则

- 配置基于ICMPv6协议类型、源IPv6地址（主机地址）和目的IPv6地址（网段地址）过滤报文的规则

在ACL6 3001中配置规则，允许源IPv6地址是fc00:1::1主机地址且目的IPv6地址是fc00:2::/64网段的ICMPv6报文通过。

```
<Huawei> system-view
[Huawei] acl ipv6 3001
[Huawei-acl6-adv-3001] rule permit icmpv6 source fc00:1::1 128 destination fc00:2:: 64
```

- **配置基于TCP协议类型、TCP目的端口号、源IPv6地址（主机地址）和目的IPv6地址（网段地址）过滤报文的规则**

在名称为deny-telnet的高级ACL6中配置规则，拒绝源IPv6地址是fc00:1::3的主机与目的IP地址是fc00:2::/64网段的主机建立Telnet连接。

```
<Huawei> system-view
[Huawei] acl ipv6 name deny-telnet
[Huawei-acl6-adv-deny-telnet] rule deny tcp destination-port eq telnet source fc00:1::3 128 destination fc00:2:: 64
```

在名称为no-web的高级ACL6中配置规则，禁止fc00:1::3和fc00:1::4两台主机访问Web网页（HTTP协议用于网页浏览，对应TCP端口号是80）。

```
<Huawei> system-view
[Huawei] acl ipv6 name no-web
[Huawei-acl6-adv-no-web] rule deny tcp destination-port eq 80 source fc00:1::3 128
[Huawei-acl6-adv-no-web] rule deny tcp destination-port eq 80 source fc00:1::4 128
```

- **配置基于时间的ACL6规则**
请参见“配置基本ACL”中的[配置基于时间的ACL规则](#)，不再赘述。
- **配置基于IP分片信息、源IP地址（网段地址）过滤报文的规则**
请参见“配置基本ACL”中的[配置基于IP分片信息、源IP地址（网段地址）过滤报文的规则](#)，不再赘述。

5.7.6.3 应用高级 ACL6

背景信息

配置完ACL6后，必须在具体的业务模块中应用ACL6，才能使ACL6正常下发和生效。

最基本的ACL6应用方式，是在简化流策略/流策略中应用ACL6，使设备能够基于全局或接口下发ACL6，实现对转发报文的过滤。此外，ACL6还可以应用在FTP、组播等模块。

操作步骤

步骤1 应用高级ACL6。

高级ACL6的常见应用方式，如[表5-20](#)所示。

表 5-20 应用高级 ACL6

业务分类	应用场景	各业务模块的ACL应用方式
对转发的报文进行过滤	基于全局和接口，对转发的报文进行过滤，从而使设备能够进一步对过滤出的报文进行丢弃、修改优先级、重定向等处理。 例如，可以利用ACL6，降低P2P下载、网络视频等消耗大量带宽的数据流的服务等级，在网络拥塞时优先丢弃这类流量，减少它们对其他重要流量的影响。	• 简化流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“基于ACL的简化流策略配置” • 流策略：请参见《 AR300, AR700 配置指南-QoS 》中的“MQC 配置” • 包过滤防火墙：请参见《 AR300, AR700 配置指南-防火墙配置 》中的“6.7 配置包过滤防火墙” 说明 仅包过滤防火墙业务支持通过rule（高级ACL6视图）命令，配置高级ACL6规则匹配报文的源/目的地址是通过DHCPv6 PD前缀名称获取的IPv6地址前缀。在同一个ACL6规则中，不能同时配置destination pd destination-dhcpv6-prefix和source pd source-dhcpv6-prefix参数。
登录控制	对设备的登录权限进行控制，允许合法用户登录，拒绝非法用户登录，从而有效防止未经授权用户的非法接入，保证网络安全。 例如，一般情况下设备只允许管理员登录，非管理员用户不允许随意登录。这时就可以在Telnet中应用ACL6，并在ACL6中定义哪些主机可以登录，哪些主机不能。	• Telnet：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置Telnet服务器功能” • FTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过FTP进行文件操作” • SFTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过SFTP进行文件操作”

业务分类	应用场景	各业务模块的ACL应用方式
路由过滤	ACL6可以应用在组播协议中，实现组播组的过滤。 例如，可以将ACL6和MLD Snooping配合使用，禁止VLAN内的主机加入指定组播组。	组播：请参见《 AR300, AR700 配置指南-IP组播 》中的“配置MLD Snooping策略的配置组播组过滤策略”、“配置IGMP Snooping策略的配置组播组过滤策略”、“配置根据源地址过滤IGMP报文”和“”

----结束

5.7.6.4 检查高级 ACL6 配置结果

操作步骤

- 执行命令**display acl ipv6 { acl6-number | name acl6-name | all }**，查看ACL6的配置信息。
- 执行命令**display time-range { all | time-name }**，查看时间段信息。

----结束

5.8 维护 ACL

介绍如何维护ACL。

5.8.1 调整 ACL 规则的步长

背景信息

在网络日常维护过程中，已部署的ACL可能无法满足新的业务需求，需要管理员为原ACL添加新的规则。由于ACL的缺省步长是5（即系统自动为ACL规则分配编号时的相邻规则编号之间的差值是5，例如rule 5、rule 10、rule 15...），所以管理员在系统分配的相邻编号的规则之间，最多只能插入4条规则（rule 6、rule 7、rule 8、rule 9）。如果新业务要求在这两个规则之间插入4条以上的规则，则可以将ACL规则的步长调大到6以上，使系统按照新步长重新调整规则编号（rule 6、rule 12、rule 18...），从而可以方便的插入4条以上的新规则（rule 7、rule 8、rule 9、rule 10、rule 11）。

关于步长的详细介绍，请参见[5.2.3 ACL的步长设定](#)。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 创建ACL，可使用编号或者名称两种方式创建。

- 执行命令[acl \[number \] acl-number \[match-order { auto | config } \]](#)，使用编号（2000～4999或者6000～6031）创建一个数字型的ACL，并进入ACL视图。
- 执行命令[acl name acl-name \[advance | basic | link | acl-number \] \[match-order { auto | config } \]](#)，使用名称创建一个命名型的ACL，并进入ACL视图。

缺省情况下，未创建ACL。

关于数字型ACL和命名型ACL的详细介绍，请参见[5.2.2 ACL的分类](#)。

步骤3 执行命令[step step](#)，配置ACL步长。

缺省情况下，步长值为5。

----结束

5.8.2 查看 ACL 的资源信息

背景信息

当用户发现应用ACL时设备提示失败，原因之一可能是设备上的ACL资源已分配完毕。

为了确认设备ACL资源的分配情况，可以查看ACL的资源信息。

操作步骤

- 在任意视图下执行命令[display acl resource \[slot slot-id \]](#)，查看ACL的资源信息。

显示信息中的Remaining计数非零，表示设备仍存在空余的ACL资源。

----结束

5.8.3 优化 ACL 资源

当配置占用ACL资源的业务时，如果设备提示ACL资源不足，则表明设备的ACL资源已经超限。此时，除了可以删除非必需配置的业务以空出ACL资源外，还可以对ACL应用的范围进行调整或者对业务配置中的ACL规则进行合并，从而节省ACL资源。以流策略为例（流策略占用的ACL资源计算方法请参见《AR300, AR700 配置指南-QoS》中的“MQC配置-配置注意事项”）。

假设使用命令[if-match acl { acl-number | acl-name }](#)配置了1K条规则，并且将引用ACL的流策略应用在8个接口的outbound方向上，该配置实际需要占用的ACL资源为8K，大于设备支持的下行ACL资源规格（假设为7K），此时该业务无法配置成功。通过以下两种方式，可以减少该业务占用的ACL资源，从而可以顺利配置成功。

- 方式一：调整ACL应用范围

如果应用流策略的接口均在同一个VLAN，或者部分接口在同一个VLAN，并且未应用流策略的接口均不属于这些VLAN，则可以将ACL应用在各接口所属的VLAN下（假设为VLAN 10和VLAN 20）。调整应用范围后，上例占用的ACL资源为1K（规则数）×2（VLAN数）=2K条，满足设备ACL资源规格的限制。

- 方式二：合并ACL规则

分析各ACL规则公用的匹配项，找出各规则之间的联系。

假设，1K条ACL规则中包含以下内容：

```
#  
acl number 3009
```

```
rule 1 permit ip source 10.1.1.1 0 destination 10.10.1.1 0
rule 2 permit ip source 10.1.1.2 0 destination 10.10.1.1 0
rule 3 permit ip source 10.1.1.3 0 destination 10.10.1.1 0
rule 4 permit ip source 10.1.1.4 0 destination 10.10.1.1 0
...
rule 255 permit ip source 10.1.1.255 0 destination 10.10.1.1 0
rule 256 permit ip source 10.1.2.1 0 destination 10.10.1.1 0
...
rule 510 permit ip source 10.1.2.255 0 destination 10.10.1.1 0
...
rule 801 deny tcp destination-port eq www //80端口
rule 802 deny tcp destination-port eq 81
rule 803 deny tcp destination-port eq 82
...
rule 830 deny tcp destination-port eq pop2 //109端口
rule 831 deny tcp destination-port eq pop3 //110端口
...
rule 1000 xxx
#
```

由于rule 1 ~ rule 510均用到了匹配项源IP地址和目的IP地址，且源IP地址覆盖了10.1.1.0/24和10.1.2.0/24两个网段的所有地址，因此可以利用IP地址通配符掩码，将rule 1 ~ rule 510合并成以下两条规则：

```
#
acl number 3009
rule 1 permit ip source 10.1.1.0 0.0.0.255 destination 10.10.1.1 0
rule 2 permit ip source 10.1.2.0 0.0.0.255 destination 10.10.1.1 0
...
#
```

合并规则后，上例中的规则减少到492条，占用ACL资源数降低到492（规则数）× 8（接口数）=3936条，满足设备ACL资源规格的限制。

5.8.4 清除 ACL 的统计信息

背景信息

须知

清除统计信息后，以前的统计信息将无法恢复，请务必仔细确认。

操作步骤

- 在确认需要清除ACL的运行信息后，请在用户视图下执行**reset acl counter { name acl-name | acl-number | all }**命令，清除ACL统计信息。
- 在确认需要清除ACL6的运行信息后，请在用户视图下执行**reset acl ipv6 counter { name acl6-name | acl6-number | all }**命令，清除ACL6统计信息。

----结束

5.9 ACL 配置举例

5.9.1 使用基本 ACL 限制 FTP 访问权限示例

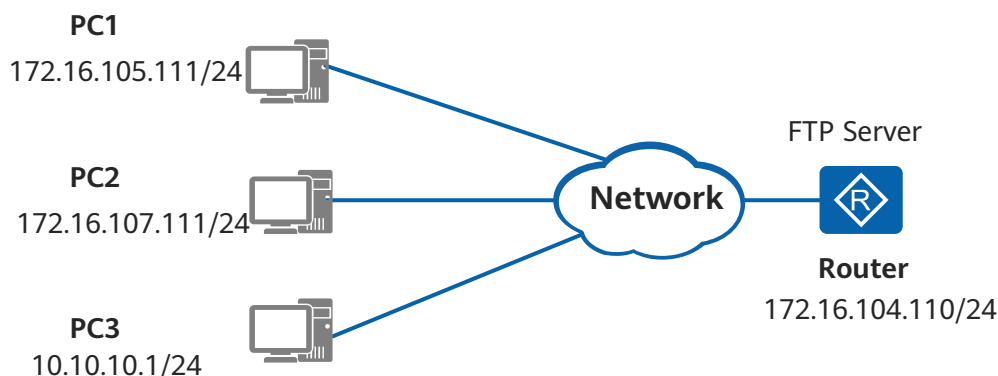
组网需求

如图5-12所示，Router作为FTP服务器，对网络中的不同用户开放不同的访问权限：

- 子网1（172.16.105.0/24）的所有用户在任何时间都可以访问FTP服务器。
- 子网2（172.16.107.0/24）的所有用户只能在某一个时间范围内访问FTP服务器。
- 其他用户不可以访问FTP服务器。

已知Router与各个子网之间路由可达，要求在Router上进行配置，实现FTP服务器对客户端访问权限的设置。

图 5-12 使用基本 ACL 限制 FTP 访问权限组网图



配置思路

采用如下的思路在Router上进行配置：

1. 配置时间段和ACL，使设备可以基于时间的ACL对网络中不同用户的报文进行过滤，从而控制不同用户的FTP访问权限。
2. 配置FTP基本功能。
3. 在FTP模块中应用ACL，使ACL生效。

操作步骤

步骤1 配置时间段

```
<Huawei> system-view
[Huawei] sysname Router
[Router] time-range ftp-access from 0:0 2014/1/1 to 23:59 2014/12/31
[Router] time-range ftp-access 14:00 to 18:00 off-day
```

步骤2 配置基本ACL

```
[Router] acl number 2001
[Router-acl-basic-2001] rule permit source 172.16.105.0 0.0.0.255
[Router-acl-basic-2001] rule permit source 172.16.107.0 0.0.0.255 time-range ftp-access
[Router-acl-basic-2001] rule deny source any
[Router-acl-basic-2001] quit
```

步骤3 配置FTP基本功能

```
[Router] ftp server permit interface all
[Router] ftp server enable
[Router] aaa
```

```
[Router-aaa] local-user huawei password irreversible-cipher YsHsjx_202206
[Router-aaa] local-user huawei privilege level 15
[Router-aaa] local-user huawei service-type ftp
[Router-aaa] local-user huawei ftp-directory flash:
[Router-aaa] quit
```

步骤4 配置FTP服务器访问权限

```
[Router] ftp acl 2001
```

步骤5 验证配置结果

在子网1的PC1（172.16.105.111/24）上执行**ftp 172.16.104.110**命令，可以连接FTP服务器。

2014年某个周一在子网2的PC2（172.16.107.111/24）上执行**ftp 172.16.104.110**命令，不能连接FTP服务器；2014年某个周六下午15:00在子网2的PC2（172.16.107.111/24）上执行**ftp 172.16.104.110**命令，可以连接FTP服务器。

在PC3（10.10.10.1/24）上执行**ftp 172.16.104.110**命令，不能连接FTP服务器。

----结束

配置文件

Router的配置文件

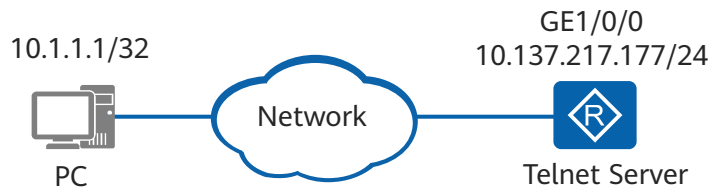
```
#
sysname Router
#
time-range ftp-access 14:00 to 18:00 off-day
time-range ftp-access from 00:00 2014/1/1 to 23:59 2014/12/31
#
acl number 2001
rule 5 permit source 172.16.105.0 0.0.0.255
rule 10 permit source 172.16.107.0 0.0.0.255 time-range ftp-access
rule 15 deny
#
aaa
local-user huawei password irreversible-cipher %^%#a/sUWg/.p1*)=--SWzIRS0N",`&aS%'7X).m=o[PkQcv"!!
TTQOI~Z)C'1<9%^%#
local-user huawei privilege level 15
local-user huawei ftp-directory flash:
local-user huawei service-type ftp
#
ftp server permit interface all
ftp server enable
ftp acl 2001
#
return
```

5.9.2 使用基本 ACL 限制 Telnet 登录权限示例

组网需求

如图5-13所示，PC与设备之间路由可达，用户希望简单方便的配置和管理远程设备，可以在服务器端配置Telnet用户使用AAA认证登录，并配置基于ACL的安全策略，保证只有符合安全策略的用户才能登录设备。

图 5-13 配置通过 Telnet 登录设备组网图



说明

使用Telnet协议存在安全风险，建议使用STelnet V2登录设备。

配置思路

采用如下的思路进行配置：

1. 配置Telnet方式登录设备，以实现远程维护网络设备。
2. 配置基于ACL的安全策略，保证只有符合安全策略的用户才能登录设备。
3. 配置管理员的用户名和密码，并配置AAA认证策略，保证只有认证通过的用户才能登录设备。

操作步骤

步骤1 配置服务器的端口号以及使能服务器功能

```
<Huawei> system-view
[Huawei] sysname Telnet Server
[Telnet Server] telnet server permit interface all//配置Telnet服务器允许客户端连接的接口，否则无法使能Telnet服务。
[Telnet Server] telnet server enable
[Telnet Server] telnet server port 1025
```

步骤2 配置VTY用户界面的相关参数

配置VTY用户界面的最大个数。

```
[Telnet Server] user-interface maximum-vty 8
```

配置允许用户登录设备的主机地址。

```
[Telnet Server] acl 2001
[Telnet Server-acl-basic-2001] rule permit source 10.1.1.1 0
[Telnet Server-acl-basic-2001] quit
[Telnet Server] user-interface vty 0 7
[Telnet Server-ui-vty0-7] acl 2001 inbound
```

配置VTY用户界面的终端属性。

```
[Telnet Server-ui-vty0-7] shell
[Telnet Server-ui-vty0-7] idle-timeout 20
[Telnet Server-ui-vty0-7] screen-length 30
[Telnet Server-ui-vty0-7] history-command max-size 20
```

配置VTY用户界面的用户验证方式。

```
[Telnet Server-ui-vty0-7] authentication-mode aaa
[Telnet Server-ui-vty0-7] quit
```

步骤3 配置登录用户的相关信息

配置登录验证方式。


```
[Telnet Server] aaa
[Telnet Server-aaa] local-user admin1234 password irreversible-cipher YsHsjx_202206
[Telnet Server-aaa] local-user admin1234 service-type telnet
[Telnet Server-aaa] local-user admin1234 privilege level 3
[Telnet Server-aaa] quit
```

步骤4 客户端登录

进入管理员PC的Windows命令行提示符，执行相关命令，通过Telnet方式登录设备。

```
C:\Documents and Settings\Administrator> telnet 10.137.217.177 1025
```

输入Enter键后，在登录窗口输入AAA验证方式配置的登录用户名和密码，验证通过后，出现用户视图的命令行提示符，至此用户成功登录设备。

```
Login authentication
```

```
Username:admin1234
```

```
Password:
```

```
<Telnet Server>
```

----结束

配置文件

Telnet Server的配置文件

```
#
sysname Telnet Server
#
acl number 2001
rule 5 permit source 10.1.1.1 0
#
aaa
local-user admin1234 password irreversible-cipher %^%#*~Br";[g6Pv5Zf>$~{hY+N!`{$<[Y{;l02P)B,EBz\1FN!c
+%^%#
local-user admin1234 privilege level 3
local-user admin1234 service-type telnet
#
telnet server permit interface all
telnet server enable
telnet server port 1025
#
user-interface maximum-vty 8
user-interface vty 0 7
acl 2001 inbound
authentication-mode aaa
history-command max-size 20
idle-timeout 20 0
screen-length 30
#
return
```

5.9.3 SNMP 中应用基本 ACL 过滤非法网管示例（SNMPv1）

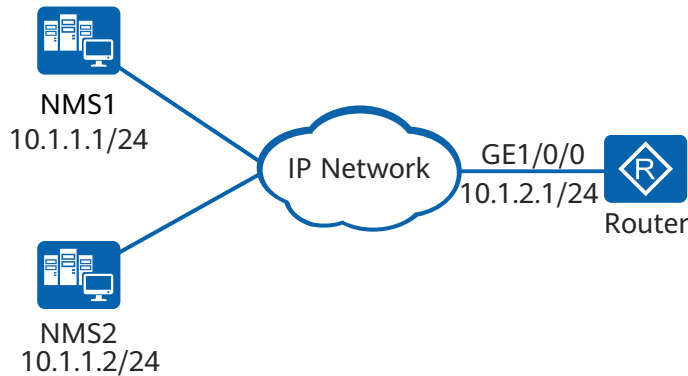
组网需求

如图5-14所示，网络中存在两个网管可以对网络中的设备进行监管。由于网络规模较小、安全性较高，管理员希望Router使用SNMPv1版本与网管进行通信，并且只有可信任的网管（NMS2）才能管理Router，禁止非法网管管理Router。此外，根据业务需要，管理员希望网管站只对设备的DNS节点进行管理，并且通过网管站的管理，可以让管理员能够快速地进行故障定位和排除。

说明

建议选择安全的SNMPv3协议，如果采用SNMPv1协议，可能导致安全风险。安全的举例请参见[SNMP中应用基本ACL过滤非法网管示例（SNMPv3）](#)。

图 5-14 SNMP 中应用基本 ACL 过滤非法网管组网图



配置思路

采用如下的配置思路：

1. 配置路由器的SNMP版本为SNMPv1。
2. 配置ACL、MIB视图和团体名，控制网管站的访问权限，使NMS2可以管理Router上RMON之外的节点，NMS1不能管理Router。
3. 配置路由器的Trap功能，使路由器产生的告警能够发送至NMS2。为了方便对告警信息进行定位，避免过多的无用告警对处理问题造成干扰，仅允许缺省打开的模块可以发送告警。
4. 配置路由器管理员的联系方式，以便路由器出现故障时网管管理员能快速联系上就近的设备管理员，以便对故障进行快速定位和排除。
5. 配置网管站（仅NMS2）。

操作步骤

步骤1 配置路由器的IP地址和路由，使和网管站之间路由可达

```
<Huawei> system-view
[Huawei] sysname Router
[Router] interface gigabitethernet 1/0/0
[Router-GigabitEthernet1/0/0] ip address 10.1.2.1 24
[Router-GigabitEthernet1/0/0] quit
[Router] ospf
[Router-ospf-1] area 0
[Router-ospf-1-area-0.0.0.0] network 10.1.2.0 0.0.0.255
[Router-ospf-1-area-0.0.0.0] quit
[Router-ospf-1] quit
```

步骤2 配置设备允许NMS通过合法的物理接口连接。

```
[Router] snmp-agent permit interface gigabitethernet 1/0/0 //如果不配置此步骤无法开启SNMP服务功能。
```

步骤3 使能SNMP Agent

```
[Router] snmp-agent
```

步骤4 配置Router的SNMP版本为SNMPv1

```
[Router] snmp-agent sys-info version v1
```

步骤5 配置网管站的访问权限

配置ACL，使NMS2可以管理Router，NMS1不允许管理Router。

```
[Router] acl 2001
[Router-acl-basic-2001] rule 5 permit source 10.1.1.2 0.0.0.0
[Router-acl-basic-2001] rule 6 deny source 10.1.1.1 0.0.0.0
[Router-acl-basic-2001] quit
```

配置MIB视图。

```
[Router] snmp-agent mib-view iso include iso
```

配置设备发送Trap的源接口。

```
[Router] snmp-agent trap source gigabitethernet 1/0/0
```

配置团体名并引用ACL和MIB视图。

```
[Router] snmp-agent community write adminnms2 mib-view iso acl 2001
```

步骤6 配置告警功能

```
[Router] snmp-agent target-host trap-paramsname trapnms2 v1 securityname adminnms2
[Router] snmp-agent target-host trap-hostname nms2 address 10.1.1.2 trap-paramsname trapnms2
[Router] snmp-agent trap queue-size 200
[Router] snmp-agent trap life 60
[Router] snmp-agent trap enable
```

步骤7 配置设备管理员联系方式

```
[Router] snmp-agent sys-info contact call Operator at 010-12345678
```

步骤8 配置网管站（NMS2）

在使用SNMPv1版本的NMS上需要设置“读写团体名”。网管的配置请根据采用的网管产品参考对应的网管配置手册。

 说明

网管系统的认证参数配置必须和设备上保持一致，否则网管系统无法管理设备。如果设备上只配置了write团体名，那么网管端读和写团体名都用设备上配置的write团体名。

步骤9 验证配置结果

配置完成后，可以执行下面的命令，检查配置内容是否生效。

查看SNMP版本。

```
<Router> display snmp-agent sys-info version
SNMP version running in the system:
SNMPv1
```

查看团体名的配置信息。

```
<Router> display snmp-agent community write
Community name: %^%#X!5#d+t+OJOXL1[{O2!&Fe&0UZv'@a;R/'Y+kK$4BUGFe)&2YLuM/kMF!
HPG5Mzz3DXe2&F%^%#
Storage type: nonVolatile
View name: iso
Acl: 2001

Total number is 1
```

查看ACL配置。

```
<Router> display acl 2001
Basic ACL 2001, 2 rules
Acl's step is 5
rule 5 permit source 10.1.1.2 0
rule 6 deny source 10.1.1.1 0
```

查看MIB视图。

```
<Router> display snmp-agent mib-view iso
View name: iso
MIB subtree: iso
Subtree mask:
Storage type: nonVolatile
View type: included
View status: active
```

查看告警的目标主机。

```
<Router> display snmp-agent target-host
Traphost list:
Target host name: nms2
Traphost address: 10.1.1.2
Traphost portnumber: 162
Target host parameter: trapnms2

Total number is 1

Parameter list trap target host:
Parameter name of the target host: trapnms2
Message mode of the target host: SNMPV1
Trap version of the target host: v1
Security name of the target host: %^%#_XqAFC_94uCS,3'<gYC*ZU6%^%#

Total number is 1
```

配置设备管理员联系方式。

```
<Router> display snmp-agent sys-info contact
The contact person for this managed node:
call Operator at 010-12345678
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
acl number 2001
rule 5 permit source 10.1.1.2 0
rule 6 deny source 10.1.1.1 0
#
interface GigabitEthernet1/0/0
ip address 10.1.2.1 255.255.255.0
#
ospf 1
area 0.0.0.0
network 10.1.2.0 0.0.0.255
#
snmp-agent local-engineid 800007DB03548998F3A458
snmp-agent community write %^%#$X!5#d+t+OJOXL1[{O2!&Fe&0UZv'@a;R/'Y+kK$4BUGFe)&2YLuM/kMF!
HPG5Mzz3DXe2&F%^%# mib-view iso acl 2001
snmp-agent sys-info contact call Operator at 010-12345678
snmp-agent sys-info version v1
snmp-agent target-host trap-hostname nms2 address 10.1.1.2 udp-port 162 trap-paramsname trapnms2
snmp-agent target-host trap-paramsname trapnms2 v1 securityname %^
%^#_XqAFC_94uCS,3'<gYC*ZU6%^%#
```

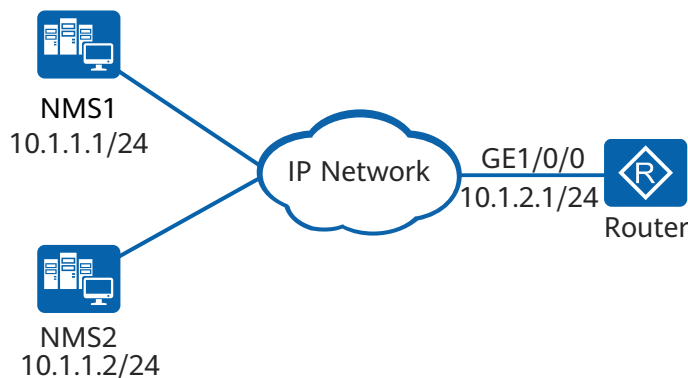
```
snmp-agent mib-view iso include iso
snmp-agent trap source gigabitethernet 1/0/0
snmp-agent trap enable
snmp-agent trap queue-size 200
snmp-agent trap life 60
snmp-agent
#
return
```

5.9.4 SNMP 中应用基本 ACL 过滤非法网管示例（SNMPv3）

组网需求

如图5-15所示，网络中存在两个网管可以对网络中的设备进行监管。由于网络规模较小、安全性较高，管理员希望Router使用SNMPv3版本与网管进行通信，并且只有可信任的网管（NMS2）才能管理Router，禁止非法网管管理Router。此外，根据业务需要，管理员希望网管站只对设备的DNS节点进行管理，并且通过网管站的管理，可以让管理员能够快速的进行故障定位和排除。

图 5-15 SNMP 中应用基本 ACL 过滤非法网管组网图



配置思路

采用如下的配置思路：

1. 配置路由器的SNMP版本为SNMPv3。
2. 配置ACL、MIB视图和团体名，控制网管站的访问权限，使NMS2可以管理Router上RMON之外的节点，NMS1不能管理Router。
3. 配置路由器的Trap功能，使路由器产生的告警能够发送至NMS2。为了方便对告警信息进行定位，避免过多的无用告警对处理问题造成干扰，仅允许缺省打开的模块可以发送告警。
4. 配置路由器管理员的联系方式，以便路由器出现故障时网管管理员能快速联系上就近的设备管理员，以便对故障进行快速定位和排除。
5. 配置网管站（仅NMS2）。

操作步骤

步骤1 配置路由器的IP地址和路由，使和网管站之间路由可达

```
<Huawei> system-view
[Huawei] sysname Router
[Router] interface gigabitethernet 1/0/0
[Router-GigabitEthernet1/0/0] ip address 10.1.2.1 24
[Router-GigabitEthernet1/0/0] quit
[Router] ospf
[Router-ospf-1] area 0
[Router-ospf-1-area-0.0.0.0] network 10.1.2.0 0.0.0.255
[Router-ospf-1-area-0.0.0.0] quit
[Router-ospf-1] quit
```

步骤2 配置设备允许NMS通过合法的物理接口连接。

```
[Router] snmp-agent permit interface gigabitethernet 1/0/0 //如果不配置此步骤无法开启SNMP服务功能。
```

步骤3 使能SNMP Agent

```
[Router] snmp-agent
```

步骤4 配置Router的SNMP版本为SNMPv3

```
[Router] snmp-agent sys-info version v3
```

步骤5 配置网管站的访问权限

配置ACL，使NMS2可以管理Router，NMS1不允许管理Router。

```
[Router] acl 2001
[Router-acl-basic-2001] rule 5 permit source 10.1.1.2 0.0.0.0
[Router-acl-basic-2001] rule 6 deny source 10.1.1.1 0.0.0.0
[Router-acl-basic-2001] quit
```

配置MIB视图。

```
[Router] snmp-agent mib-view iso include iso
```

 说明

如果配置鉴权或鉴权且加密，请务必执行命令**snmp-agent mib-view view-name include subtree-name**，配置MIB视图的信息且包括该MIB子树。

配置设备发送Trap的源接口。

```
[Router] snmp-agent trap source gigabitethernet 1/0/0
```

配置用户组和用户，对数据进行认证和加密。

```
[Router] snmp-agent usm-user v3 testuser
[Router] snmp-agent group v3 testgroup privacy
[Router] snmp-agent usm-user v3 testuser group testgroup
[Router] snmp-agent usm-user v3 testuser authentication-mode sha2-256
Please configure the authentication password (<8-64>)
Enter Password:
Confirm password:
[Router] snmp-agent usm-user v3 testuser privacy-mode aes128
Please configure the privacy password (<8-64>)
Enter Password:
Confirm password:
[Router] snmp-agent group v3 testgroup privacy write-view iso notify-view iso acl 2001
```

步骤6 配置告警功能

```
[Router] snmp-agent target-host trap-paramsname trapnms2 v3 securityname testuser privacy
[Router] snmp-agent target-host trap-hostname nms2 address 10.1.1.2 trap-paramsname trapnms2
[Router] snmp-agent trap queue-size 200
[Router] snmp-agent trap life 60
[Router] snmp-agent trap enable
```

步骤7 配置设备管理员联系方式

```
[Router] snmp-agent sys-info contact call Operator at 010-12345678
```

步骤8 配置网管站（NMS2）

在使用SNMP v3版本的NMS上需要设置“用户组和用户”。网管的配置请根据采用的网管产品参考对应的网管配置手册。

说明

网管系统的认证参数配置必须和设备上保持一致，否则网管系统无法管理设备。

步骤9 验证配置结果

配置完成后，可以执行下面的命令，检查配置内容是否生效。

查看用户组。

```
<Router> display snmp-agent group testgroup
Group name: testgroup
Security model: v3 AuthPriv
Readview: ViewDefault
Writeview: iso
Notifyview: iso
Storage type: nonVolatile
Acl: 2001
```

查看用户。

```
<Router> display snmp-agent usm-user
User name: testuser
Engine ID: 800007DB03548998F3A458
Group name: testgroup
Authentication mode: sha2-256, Privacy mode: aes128
Storage type: nonVolatile
User status: active

Total number is 1
```

查看ACL。

```
<Router> display acl 2001
Basic ACL 2001, 2 rules
ACL's step is 5
rule 5 permit source 10.1.1.2 0 (1 matches)
rule 6 deny source 10.1.1.1 0
```

查看MIB视图。

```
<Router> display snmp-agent mib-view iso
View name: iso
MIB subtree: iso
Subtree mask:
Storage type: nonVolatile
View type: included
View status: active
```

查看告警的目标主机。

```
<Router> display snmp-agent target-host
Traphost list:
Target host name: nms2
Traphost address: 10.1.1.2
Traphost portnumber: 162
Target host parameter: trapnms2

Total number is 1

Parameter list trap target host:
Parameter name of the target host: trapnms2
Message mode of the target host: SNMPV3
```

```
Trap version of the target host: v3
Security name of the target host: %@@@_XqAFC_94uCS,3'<gYC*ZU6%@@@
Security level of the target host: privacy

Total number is 1
```

配置设备管理员联系方式。

```
<Router> display snmp-agent sys-info contact
The contact person for this managed node:
call Operator at 010-12345678
```

----结束

配置文件

Router的配置文件

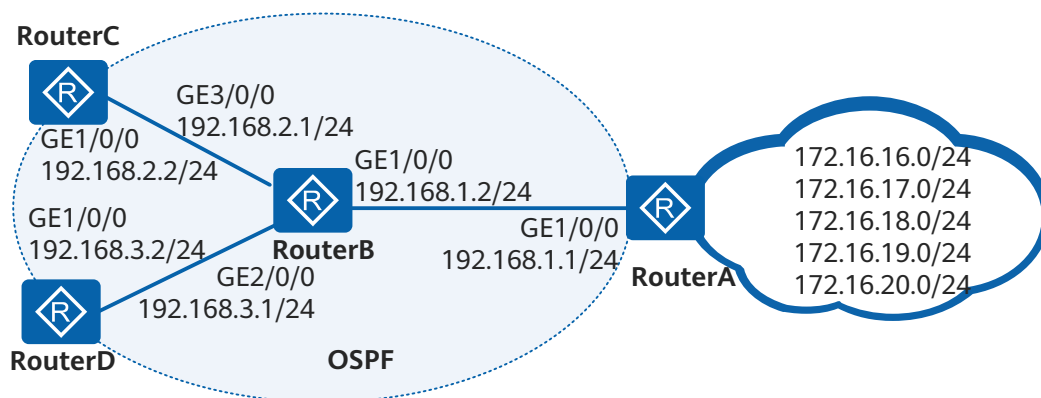
```
#
sysname Router
#
acl number 2001
rule 5 permit source 10.1.1.2 0
rule 6 deny source 10.1.1.1 0
#
interface GigabitEthernet1/0/0
ip address 10.1.2.1 255.255.255.0
#
ospf 1
area 0.0.0.0
network 10.1.2.0 0.0.0.255
#
snmp-agent local-engineid 800007DB03548998F3A458
snmp-agent sys-info contact call Operator at 010-12345678
snmp-agent group v3 testgroup privacy write-view iso notify-view iso acl 2001
snmp-agent target-host trap-hostname nms2 address 10.1.1.2 udp-port 162 trap-paramsname trapnms2
snmp-agent target-host trap-paramsname trapnms2 v3 securityname %@@@_XqAFC_94uCS,3'<gYC*ZU6%@@@ privacy
snmp-agent mib-view iso include iso
snmp-agent trap source gigabitethernet 1/0/0
snmp-agent usm-user v3 testuser
snmp-agent usm-user v3 testuser group testgroup
snmp-agent usm-user v3 testuser authentication-mode sha2-256 %@@@J>K4RVS=3Px}z#*+8Qd*"9#Z%@%@@
snmp-agent usm-user v3 testuser privacy-mode aes128 %^%#Ku=*AHm#n(q=&{=Tr%>1BV9e;]9sI5q(M=$gy]d>%^%#
snmp-agent trap enable
snmp-agent trap queue-size 200
snmp-agent trap life 60
snmp-agent
#
return
```

5.9.5 在 OSPF 中使用基本 ACL 过滤路由信息示例

组网需求

如图5-16，运行OSPF协议的网络中，RouterA从Internet网络接收路由，并为OSPF网络提供了Internet路由。要求OSPF网络中只能访问172.16.17.0/24、172.16.18.0/24和172.16.19.0/24三个网段的网络，其中RouterC连接的网络只能访问172.16.18.0/24网段的网络。

图 5-16 配置对接收和发布的路由过滤组网图



配置思路

采用如下的思路配置对路由进行过滤：

1. 在RouterA上配置ACL，在路由发布时应用ACL，使RouterA仅提供路由 172.16.17.0/24、172.16.18.0/24、172.16.19.0/24给RouterB，实现OSPF网络中只能访问172.16.17.0/24、172.16.18.0/24、172.16.19.0/24三个网段的网络。
2. 在RouterC上配置ACL，在路由引入时应用ACL，使RouterC仅接收路由 172.16.18.0/24，实现RouterC连接的网络只能访问172.16.18.0/24网段的网络。

操作步骤

步骤1 配置各接口的IP地址

配置RouterA的各接口的IP地址。

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] interface gigabitethernet 1/0/0
[RouterA-GigabitEthernet1/0/0] ip address 192.168.1.1 255.255.255.0
[RouterA-GigabitEthernet1/0/0] quit
```

RouterB、RouterC和RouterD的配置同RouterA此处略。

步骤2 配置OSPF基本功能

RouterA的配置

```
[RouterA] ospf
[RouterA-ospf-1] area 0
[RouterA-ospf-1-area-0.0.0.0] network 192.168.1.0 0.0.0.255
[RouterA-ospf-1-area-0.0.0.0] quit
[RouterA-ospf-1] quit
```

RouterB的配置

```
[RouterB] ospf
[RouterB-ospf-1] area 0
[RouterB-ospf-1-area-0.0.0.0] network 192.168.1.0 0.0.0.255
[RouterB-ospf-1-area-0.0.0.0] network 192.168.2.0 0.0.0.255
[RouterB-ospf-1-area-0.0.0.0] network 192.168.3.0 0.0.0.255
[RouterB-ospf-1-area-0.0.0.0] quit
```

RouterC的配置

```
[RouterC] ospf
[RouterC-ospf-1] area 0
[RouterC-ospf-1-area-0.0.0.0] network 192.168.2.0 0.0.0.255
[RouterC-ospf-1-area-0.0.0.0] quit
[RouterC-ospf-1] quit
```

RouterD的配置

```
[RouterD] ospf
[RouterD-ospf-1] area 0
[RouterD-ospf-1-area-0.0.0.0] network 192.168.3.0 0.0.0.255
[RouterD-ospf-1-area-0.0.0.0] quit
```

步骤3 在RouterA上配置5条静态路由，并将这些静态路由引入到OSPF协议中

```
[RouterA] ip route-static 172.16.16.0 24 NULL 0
[RouterA] ip route-static 172.16.17.0 24 NULL 0
[RouterA] ip route-static 172.16.18.0 24 NULL 0
[RouterA] ip route-static 172.16.19.0 24 NULL 0
[RouterA] ip route-static 172.16.20.0 24 NULL 0
[RouterA] ospf
[RouterA-ospf-1] import-route static
[RouterA-ospf-1] quit
```

在RouterB上查看IP路由表，可以看到OSPF引入的5条静态路由。

```
[RouterB] display ip routing-table
Route Flags: R - relay, D - download to fib, T - to vpn-instance
-----
Routing Tables: Public
      Destinations : 18      Routes : 18

Destination/Mask    Proto    Pre  Cost    Flags NextHop        Interface
-----
127.0.0.0/8         Direct  0    0        D  127.0.0.1    InLoopBack0
127.0.0.1/32        Direct  0    0        D  127.0.0.1    InLoopBack0
127.255.255.255/32  Direct  0    0        D  127.0.0.1    InLoopBack0
172.16.16.0/24      O_ASE   150  1        D  192.168.1.1  GigabitEthernet1/0/0
172.16.17.0/24      O_ASE   150  1        D  192.168.1.1  GigabitEthernet1/0/0
172.16.18.0/24      O_ASE   150  1        D  192.168.1.1  GigabitEthernet1/0/0
172.16.19.0/24      O_ASE   150  1        D  192.168.1.1  GigabitEthernet1/0/0
172.16.20.0/24      O_ASE   150  1        D  192.168.1.1  GigabitEthernet1/0/0
192.168.1.0/24      Direct  0    0        D  192.168.1.2  GigabitEthernet1/0/0
192.168.1.2/32      Direct  0    0        D  127.0.0.1    GigabitEthernet1/0/0
192.168.1.255/32    Direct  0    0        D  127.0.0.1    GigabitEthernet1/0/0
192.168.2.0/24      Direct  0    0        D  192.168.2.1  GigabitEthernet3/0/0
192.168.2.1/32      Direct  0    0        D  127.0.0.1    GigabitEthernet3/0/0
192.168.2.255/32    Direct  0    0        D  127.0.0.1    GigabitEthernet3/0/0
192.168.3.0/24      Direct  0    0        D  192.168.3.1  GigabitEthernet2/0/0
192.168.3.1/32      Direct  0    0        D  127.0.0.1    GigabitEthernet2/0/0
192.168.3.255/32    Direct  0    0        D  127.0.0.1    GigabitEthernet2/0/0
255.255.255.255/32  Direct  0    0        D  127.0.0.1    InLoopBack0
```

步骤4 配置路由发布策略。

在RouterA配置ACL 2002，允许172.16.17.0/24、172.16.18.0/24和172.16.19.0/24通过。

```
[RouterA] acl number 2002
[RouterA-acl-basic-2002] rule permit source 172.16.17.0 0.0.0.255
[RouterA-acl-basic-2002] rule permit source 172.16.18.0 0.0.0.255
[RouterA-acl-basic-2002] rule permit source 172.16.19.0 0.0.0.255
[RouterA-acl-basic-2002] quit
```

在RouterA配置发布策略，引用ACL 2002进行过滤。

```
[RouterA] ospf
[RouterA-ospf-1] filter-policy 2002 export static
[RouterA-ospf-1] quit
```

在RouterB查看IP路由表，可以看到RouterB仅接收到ACL 2002中定义的3条路由。

```
[RouterB] display ip routing-table
Route Flags: R - relay, D - download to fib
-----
Routing Tables: Public
  Destinations : 16      Routes : 16

Destination/Mask    Proto Pre  Cost   Flags NextHop         Interface
-----
 127.0.0.0/8        Direct 0    0       D 127.0.0.1      InLoopBack0
 127.0.0.1/32        Direct 0    0       D 127.0.0.1      InLoopBack0
127.255.255.255/32  Direct 0    0       D 127.0.0.1      InLoopBack0
172.16.17.0/24      O_ASE 150  1       D 192.168.1.1    GigabitEthernet1/0/0
172.16.18.0/24      O_ASE 150  1       D 192.168.1.1    GigabitEthernet1/0/0
172.16.19.0/24      O_ASE 150  1       D 192.168.1.1    GigabitEthernet1/0/0
192.168.1.0/24      Direct 0    0       D 192.168.1.2    GigabitEthernet1/0/0
192.168.1.2/32      Direct 0    0       D 127.0.0.1      GigabitEthernet1/0/0
192.168.1.255/32    Direct 0    0       D 127.0.0.1      GigabitEthernet1/0/0
192.168.2.0/24      Direct 0    0       D 192.168.2.1    GigabitEthernet3/0/0
192.168.2.1/32      Direct 0    0       D 127.0.0.1      GigabitEthernet3/0/0
192.168.2.255/32    Direct 0    0       D 127.0.0.1      GigabitEthernet3/0/0
192.168.3.0/24      Direct 0    0       D 192.168.3.1    GigabitEthernet2/0/0
192.168.3.1/32      Direct 0    0       D 127.0.0.1      GigabitEthernet2/0/0
192.168.3.255/32    Direct 0    0       D 127.0.0.1      GigabitEthernet2/0/0
255.255.255.255/32  Direct 0    0       D 127.0.0.1      InLoopBack0
```

步骤5 配置路由接收策略。

在RouterC配置ACL 2003，允许172.16.18.0/24通过。

```
[RouterC] acl number 2003
[RouterC-acl-basic-2003] rule permit source 172.16.18.0 0.0.0.255
[RouterC-acl-basic-2003] quit
```

在RouterC配置接收策略，引用ACL 2003进行过滤。

```
[RouterC] ospf
[RouterC-ospf-1] filter-policy 2003 import
[RouterC-ospf-1] quit
```

查看RouterC的IP路由表，可以看到RouterC的本地路由表中，仅接收了ACL 2003定义的1条路由。

```
[RouterC] display ip routing-table
Route Flags: R - relay, D - download to fib
-----
Routing Tables: Public
  Destinations : 8      Routes : 8

Destination/Mask    Proto Pre  Cost   Flags NextHop         Interface
-----
 127.0.0.0/8        Direct 0    0       D 127.0.0.1      InLoopBack0
 127.0.0.1/32        Direct 0    0       D 127.0.0.1      InLoopBack0
127.255.255.255/32  Direct 0    0       D 127.0.0.1      InLoopBack0
172.16.18.0/24      O_ASE 150  1       D 192.168.2.1    GigabitEthernet1/0/0
192.168.2.0/24      Direct 0    0       D 192.168.2.2    GigabitEthernet1/0/0
192.168.2.2/32      Direct 0    0       D 127.0.0.1      GigabitEthernet1/0/0
192.168.2.255/32    Direct 0    0       D 127.0.0.1      GigabitEthernet1/0/0
255.255.255.255/32  Direct 0    0       D 127.0.0.1      InLoopBack0
```

----结束

配置文件

- RouterA的配置文件

```
#
sysname RouterA
#
acl number 2002
```

```
rule 5 permit source 172.16.17.0 0.0.0.255
rule 10 permit source 172.16.18.0 0.0.0.255
rule 15 permit source 172.16.19.0 0.0.0.255
#
interface GigabitEthernet1/0/0
ip address 192.168.1.1 255.255.255.0
#
ospf 1
filter-policy 2002 export static
import-route static
area 0.0.0.0
network 192.168.1.0 0.0.0.255
#
ip route-static 172.16.16.0 255.255.255.0 NULL0
ip route-static 172.16.17.0 255.255.255.0 NULL0
ip route-static 172.16.18.0 255.255.255.0 NULL0
ip route-static 172.16.19.0 255.255.255.0 NULL0
ip route-static 172.16.20.0 255.255.255.0 NULL0
#
return
```

- RouterB的配置文件

```
#
sysname RouterB
#
interface GigabitEthernet1/0/0
ip address 192.168.1.2 255.255.255.0
#
interface GigabitEthernet2/0/0
ip address 192.168.3.1 255.255.255.0
#
interface GigabitEthernet3/0/0
ip address 192.168.2.1 255.255.255.0
#
ospf 1
area 0.0.0.0
network 192.168.1.0 0.0.0.255
network 192.168.2.0 0.0.0.255
network 192.168.3.0 0.0.0.255
#
return
```

- RouterC的配置文件

```
#
sysname RouterC
#
acl number 2003
rule 5 permit source 172.16.18.0 0.0.0.255
#
interface GigabitEthernet1/0/0
ip address 192.168.2.2 255.255.255.0
#
ospf 1
filter-policy 2003 import
area 0.0.0.0
network 192.168.2.0 0.0.0.255
#
ip ip-prefix in index 10 permit 172.16.18.0 24
#
return
```

- RouterD的配置文件

```
#
sysname RouterD
#
interface GigabitEthernet1/0/0
ip address 192.168.3.2 255.255.255.0
#
ospf 1
```

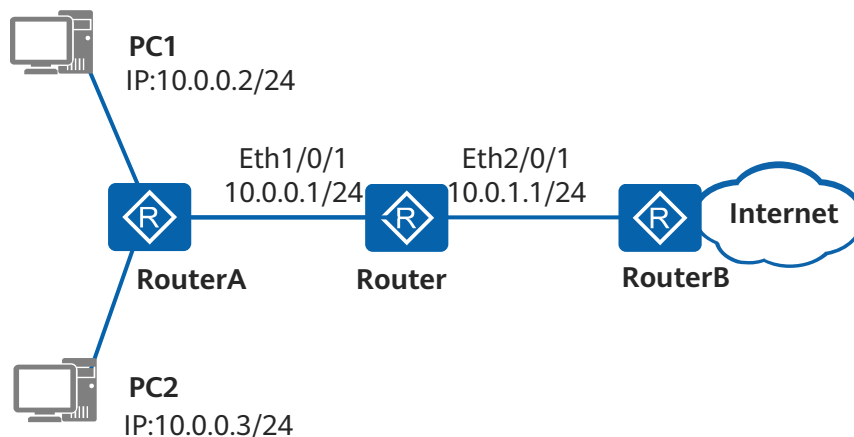
```
area 0.0.0.0
network 192.168.3.0 0.0.0.255
#
return
```

5.9.6 使用基本 ACL 实现配置 URPF 来防止基于源地址欺骗示例

组网需求

如图5-17所示，Router的Eth1/0/1接口连接用户PC1和PC2，Eth2/0/1接口连接上层路由器。为防止基于源地址欺骗攻击，要求在Eth1/0/1和Eth2/0/1接口配置URPF严格检查模式。同时，要求Router只对用户PC2（IP地址是10.0.0.3）的报文进行URPF检查。

图 5-17 使用基本 ACL 实现合法报文流免受 URPF 检查组网图



配置思路

采用如下的思路在Router上进行配置：

1. 在接口Eth1/0/1配置基于ACL的URPF功能，仅对用户PC2的报文进行URPF检查。
2. 在接口Eth2/0/1配置URPF检查模式，防止源地址欺骗攻击。

操作步骤

步骤1 配置接口Eth1/0/1的基于ACL的URPF功能，仅对用户PC2的报文进行URPF检查。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] interface ethernet 1/0/1
[Router-Ethernet1/0/1] ip address 10.0.0.1 24
[Router-Ethernet1/0/1] urpf strict acl 2001
[Router-Ethernet1/0/1] quit
[Router] acl number 2001
[Router-acl-basic-2001] rule permit source 10.0.0.3 0.0.0.255
[Router-acl-basic-2001] quit
```

步骤2 配置接口Eth2/0/1的URPF检查模式。

```
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] ip address 10.0.1.1 24
[Router-Ethernet2/0/1] urpf strict
[Router-Ethernet2/0/1] quit
```

步骤3 验证配置结果。

查看ACL规则的配置信息

```
[Router] display acl 2001
Basic ACL 2001, 1 rule
Acl's step is 5
rule 5 permit source 10.0.0.0 0.0.0.255
```

查看接口Eth1/0/1下的URPF配置信息

```
[Router] interface ethernet 1/0/1
[Router-Ethernet1/0/1] display this
#
interface Ethernet1/0/1
ip address 10.0.0.1 255.255.255.0
urpf strict acl 2001
#
return
```

查看接口Eth2/0/1的URPF配置信息

```
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] display this
#
interface Ethernet2/0/1
ip address 10.0.1.1 255.255.255.0
urpf strict
#
return
```

----结束

配置文件

Router的配置文件

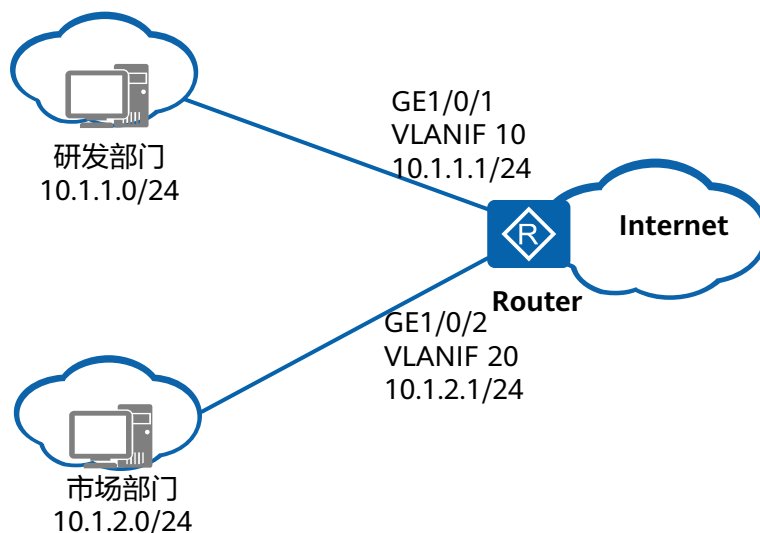
```
#
sysname Router
#
acl number 2001
rule 5 permit source 10.0.0.0 0.0.0.255
#
interface Ethernet1/0/1
ip address 10.0.0.1 255.255.255.0
urpf strict acl 2001
#
interface Ethernet2/0/1
ip address 10.0.1.1 255.255.255.0
urpf strict
#
return
```

5.9.7 使用高级 ACL 限制不同网段的用户互访示例

组网需求

如图5-18所示，某公司通过Router实现各部门之间的互连。为方便管理网络，管理员为公司的研发部和市场部规划了两个网段的IP地址。同时为了隔离广播域，又将两个部门划分在不同VLAN之中。现要求Router能够限制两个网段之间互访，防止公司机密泄露。

图 5-18 使用高级 ACL 限制不同网段的用户互访示例



配置思路

采用如下的思路在Router上进行配置：

1. 配置高级ACL和基于ACL的流分类，使设备可以对研发部与市场部互访的报文进行过滤。
2. 配置流行为，拒绝匹配上ACL规则的报文通过。
3. 配置并应用流策略，使ACL和流行为生效。

操作步骤

步骤1 配置接口所属的VLAN以及接口的IP地址

创建VLAN10和VLAN20。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20
```

配置Router的接口GE1/0/1和GE1/0/2为trunk类型接口，并分别加入VLAN10和VLAN20。

```
[Router] interface gigabitethernet 1/0/1
[Router-GigabitEthernet1/0/1] port link-type trunk
[Router-GigabitEthernet1/0/1] port trunk allow-pass vlan 10
[Router-GigabitEthernet1/0/1] quit
[Router] interface gigabitethernet 1/0/2
[Router-GigabitEthernet1/0/2] port link-type trunk
[Router-GigabitEthernet1/0/2] port trunk allow-pass vlan 20
[Router-GigabitEthernet1/0/2] quit
```

创建VLANIF10和VLANIF20，并配置各VLANIF接口的IP地址。

```
[Router] interface vlanif 10
[Router-Vlanif10] ip address 10.1.1.1 24
[Router-Vlanif10] quit
[Router] interface vlanif 20
[Router-Vlanif20] ip address 10.1.2.1 24
[Router-Vlanif20] quit
```

步骤2 配置ACL

创建高级ACL 3001并配置ACL规则，拒绝研发部访问市场部的报文通过。

```
[Router] acl 3001
[Router-acl-adv-3001] rule deny ip source 10.1.1.0 0.0.0.255 destination 10.1.2.0 0.0.0.255
[Router-acl-adv-3001] quit
```

创建高级ACL 3002并配置ACL规则，拒绝市场部访问研发部的报文通过。

```
[Router] acl 3002
[Router-acl-adv-3002] rule deny ip source 10.1.2.0 0.0.0.255 destination 10.1.1.0 0.0.0.255
[Router-acl-adv-3002] quit
```

步骤3 配置基于高级ACL的流分类

配置流分类tc1，对匹配ACL 3001和ACL 3002的报文进行分类。

```
[Router] traffic classifier tc1
[Router-classifier-tc1] if-match acl 3001
[Router-classifier-tc1] if-match acl 3002
[Router-classifier-tc1] quit
```

步骤4 配置流行为

配置流行为tb1，动作为拒绝报文通过。

```
[Router] traffic behavior tb1
[Router-behavior-tb1] deny
[Router-behavior-tb1] quit
```

步骤5 配置流策略

定义流策略，将流分类与流行为关联。

```
[Router] traffic policy tp1
[Router-trafficpolicy-tp1] classifier tc1 behavior tb1
[Router-trafficpolicy-tp1] quit
```

步骤6 在接口下应用流策略

由于研发部和市场部互访的流量分别从接口GE1/0/1和GE1/0/2进入Router，所以在接口GE1/0/1和GE1/0/2的入方向应用流策略。

```
[Router] interface gigabitethernet 1/0/1
[Router-GigabitEthernet1/0/1] traffic-policy tp1 inbound
[Router-GigabitEthernet1/0/1] quit
[Router] interface gigabitethernet 1/0/2
[Router-GigabitEthernet1/0/2] traffic-policy tp1 inbound
[Router-GigabitEthernet1/0/2] quit
```

步骤7 验证配置结果

查看ACL规则的配置信息。

```
[Router] display acl 3001
Advanced ACL 3001, 1 rule
Acl's step is 5
rule 5 deny ip source 10.1.1.0 0.0.0.255 destination 10.1.2.0 0.0.0.255
[Router] display acl 3002
Advanced ACL 3002, 1 rule
Acl's step is 5
rule 5 deny ip source 10.1.2.0 0.0.0.255 destination 10.1.1.0 0.0.0.255
```

查看流分类的配置信息。

```
[Router] display traffic classifier user-defined
User Defined Classifier Information:
Classifier: class1
```



```
Operator: OR
Rule(s) : -none-
Classifier: tc1
Operator: OR
Rule(s) :
  if-match acl 3001
  if-match acl 3002
```

查看流策略的配置信息。

```
[Router] display traffic policy user-defined tp1
User Defined Traffic Policy Information:
Policy: tp1
Classifier: tc1
Operator: OR
Behavior: tb1
  Deny
Precedence: 5
```

研发部和市场部所在的两个网段之间不能互访。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10 20
#
acl number 3001
 rule 5 deny ip source 10.1.1.0 0.0.0.255 destination 10.1.2.0 0.0.0.255
acl number 3002
 rule 5 deny ip source 10.1.2.0 0.0.0.255 destination 10.1.1.0 0.0.0.255
#
traffic classifier tc1 operator or
 if-match acl 3001
 if-match acl 3002
#
traffic behavior tb1
 deny
#
traffic policy tp1
 classifier tc1 behavior tb1 precedence 5
#
interface Vlanif10
 ip address 10.1.1.1 255.255.255.0
#
interface Vlanif20
 ip address 10.1.2.1 255.255.255.0
#
interface GigabitEthernet1/0/1
 port link-type trunk
 port trunk allow-pass vlan 10
 traffic-policy tp1 inbound
#
interface GigabitEthernet1/0/2
 port link-type trunk
 port trunk allow-pass vlan 20
 traffic-policy tp1 inbound
#
return
```

相关资料

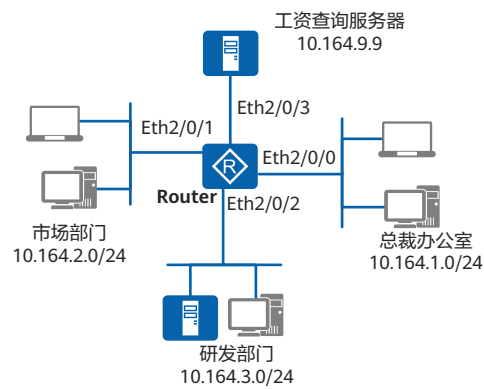
视频：[配置通过ACL禁止两个网段互访](#)

5.9.8 使用高级 ACL 限制用户在特定时间访问特定服务器的权限示例

组网需求

如图5-19所示，某公司通过Router实现各部门之间的互连。公司要求禁止研发部门和市场部门在上班时间（8:00至17:30）访问工资查询服务器（IP地址为10.164.9.9），总裁办公室不受限制，可以随时访问。

图 5-19 使用高级 ACL 限制用户在特定时间访问特定服务器的权限组网图



配置思路

采用如下的思路在Router上进行配置：

1. 配置时间段、高级ACL和基于ACL的流分类，使设备可以基于时间的ACL，对用户访问服务器的报文进行过滤，从而限制不同用户在特定时间访问特定服务器的权限。
2. 配置流行为，拒绝匹配上ACL的报文通过。
3. 配置并应用流策略，使ACL和流行为生效。

操作步骤

步骤1 配置接口加入VLAN，并配置VLANIF接口的IP地址。

将Eth2/0/0 ~ Eth2/0/2分别加入VLAN10、20、30，Eth2/0/3加入VLAN100，并配置各VLANIF接口的IP地址。下面配置以Eth2/0/0和VLANIF 10接口为例，接口Eth2/0/1、Eth2/0/2和Eth2/0/3的配置与Eth2/0/0接口类似，接口VLANIF 20、VLANIF 30和VLANIF 100的配置与VLANIF 10接口类似，不再赘述。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20 30 100
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type trunk
[Router-Ethernet2/0/0] port trunk allow-pass vlan 10
[Router-Ethernet2/0/0] quit
[Router] interface vlanif 10
[Router-Vlanif10] ip address 10.164.1.1 255.255.255.0
[Router-Vlanif10] quit
```

步骤2 配置时间段。

配置8:00至17:30的周期时间段。

```
[Router] time-range satime 8:00 to 17:30 working-day
```

步骤3 配置ACL。

配置市场部门到工资查询服务器的访问规则。

```
[Router] acl 3002
[Router-acl-3002] rule deny ip source 10.164.2.0 0.0.0.255 destination 10.164.9.9 0.0.0.0 time-range satime
[Router-acl-3002] quit
```

配置研发部门到工资查询服务器的访问规则。

```
[Router] acl 3003
[Router-acl-3003] rule deny ip source 10.164.3.0 0.0.0.255 destination 10.164.9.9 0.0.0.0 time-range satime
[Router-acl-3003] quit
```

步骤4 配置基于ACL的流分类。

配置流分类c_market，对匹配ACL 3002的报文进行分类。

```
[Router] traffic classifier c_market
[Router-classifier-c_market] if-match acl 3002
[Router-classifier-c_market] quit
```

配置流分类c_rd，对匹配ACL 3003的报文进行分类。

```
[Router] traffic classifier c_rd
[Router-classifier-c_rd] if-match acl 3003
[Router-classifier-c_rd] quit
```

步骤5 配置流行为。

配置流行为b_market，动作为拒绝报文通过。

```
[Router] traffic behavior b_market
[Router-behavior-b_market] deny
[Router-behavior-b_market] quit
```

配置流行为b_rd，动作为拒绝报文通过。

```
[Router] traffic behavior b_rd
[Router-behavior-b_rd] deny
[Router-behavior-b_rd] quit
```

步骤6 配置流策略。

配置流策略p_market，将流分类c_market与流行为b_market关联。

```
[Router] traffic policy p_market
[Router-trafficpolicy-p_market] classifier c_market behavior b_market
[Router-trafficpolicy-p_market] quit
```

配置流策略p_rd，将流分类c_rd与流行为b_rd关联。

```
[Router] traffic policy p_rd
[Router-trafficpolicy-p_rd] classifier c_rd behavior b_rd
[Router-trafficpolicy-p_rd] quit
```

步骤7 应用流策略。

由于市场部访问服务器的流量从接口Eth2/0/1进入Router，所以可以在Eth2/0/1接口的入方向应用流策略p_market。

```
[Router] interface ethernet2/0/1
[Router-Ethernet2/0/1] traffic-policy p_market inbound
[Router-Ethernet2/0/1] quit
```

由于研发部访问服务器的流量从接口Eth2/0/2进入Router，所以可以在Eth2/0/2接口的入方向应用流策略p_rd。

```
[Router] interface ethernet2/0/2
[Router-Ethernet2/0/2] traffic-policy p_rd inbound
[Router-Ethernet2/0/2] quit
```

步骤8 验证配置结果。

查看ACL规则的配置信息。

```
[Router] display acl all
Total quantity of nonempty ACL number is 2

Advanced ACL 3002, 1 rule
Acl's step is 5
rule 5 deny ip source 10.164.2.0 0.0.0.255 destination 10.164.9.9 0 time-range satime(Active)

Advanced ACL 3003, 1 rule
Acl's step is 5
rule 5 deny ip source 10.164.3.0 0.0.0.255 destination 10.164.9.9 0 time-range satime(Active)
```

查看流分类的配置信息。

```
[Router] display traffic classifier user-defined
User Defined Classifier Information:
Classifier: c_market
Operator: OR
```

```
Rule(s) :  
  if-match acl 3002  
Classifier: c_rd  
Operator: OR  
Rule(s) :  
  if-match acl 3003
```

查看流策略的配置信息。

[Router] **display traffic policy user-defined**

User Defined Traffic Policy Information:

```
Policy: p_market  
Classifier: c_market  
Operator: OR  
Behavior: b_market  
Deny  
Precedence: 5
```

```
Policy: p_rd  
Classifier: c_rd  
Operator: OR  
Behavior: b_rd  
Deny  
Precedence: 5
```

查看流策略的应用信息。

[Router] **display traffic-policy applied-record**

```
-----  
Policy Name:  p_market  
Policy Index: 6  
Classifier:c_market  Behavior:b_market  Precedence:5  
-----
```

```
*interface Ethernet2/0/1  
  traffic-policy p_market inbound  
  slot 0 : success  
-----
```

```
Policy Name:  p_rd  
Policy Index: 7  
Classifier:c_rd  Behavior:b_rd  Precedence:5  
-----
```

```
*interface Ethernet2/0/2  
  traffic-policy p_rd inbound  
  slot 0 : success  
-----
```

研发部门和市场部门在上班时间（8:00至17:30）无法访问工资查询服务器。

----结束

配置文件

Router的配置文件

```
#  
sysname Router  
#  
time-range satime 08:00 to 17:30 working-day  
#  
vlan batch 10 20 30 100  
#  
acl number 3002  
  rule 5 deny ip source 10.164.2.0 0.0.0.255 destination 10.164.9.9 0 time-range  
satime  
acl number 3003  
  rule 5 deny ip source 10.164.3.0 0.0.0.255 destination 10.164.9.9 0 time-range satime
```

```
#
traffic classifier c_market operator or
if-match acl 3002
traffic classifier c_rd operator or
if-match acl 3003
#
traffic behavior b_market
deny
traffic behavior b_rd
deny
#
traffic policy p_market
classifier c_market behavior b_market precedence 5
traffic policy p_rd
classifier c_rd behavior b_rd precedence 5
#
interface Vlanif10
ip address 10.164.1.1 255.255.255.0
#
interface Vlanif20
ip address 10.164.2.1 255.255.255.0
#
interface Vlanif30
ip address 10.164.3.1 255.255.255.0
#
interface Vlanif100
ip address 10.164.9.9 255.255.255.0
#
interface Ethernet2/0/0
port link-type trunk
port trunk allow-pass vlan 10
#
interface Ethernet2/0/1
port link-type trunk
port trunk allow-pass vlan 20
traffic-policy p_market inbound
#
interface Ethernet2/0/2
port link-type trunk
port trunk allow-pass vlan 30
traffic-policy p_rd inbound
#
interface Ethernet2/0/3
port link-type trunk
port trunk allow-pass vlan 100
#
return
```

相关资料

视频：

- [限制某时段允许上网](#)
- [限制某时段不能上网](#)

5.9.9 应用高级 ACL 配置防火墙示例

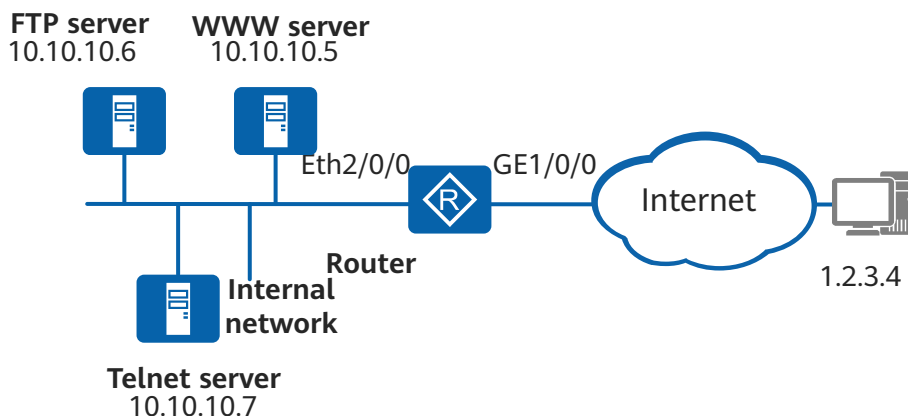
组网需求

如图5-20所示，某个对外提供Web、FTP和Telnet服务的企业通过Router的接口GE1/0/0访问外部网络，通过Router的接口Eth2/0/0加入VLAN。

已知企业的网段为10.10.10.0/24，企业内部的WWW服务器、FTP服务器和Telnet服务器IP地址分别为10.10.10.5/24、10.10.10.6/24和10.10.10.7/24。

为了实现内部网络具备较高的安全性，企业希望在Router上配置防火墙功能，使外部网络只有特定用户可以访问内部服务器，企业内只有内部服务器可以访问外部网络。

图 5-20 应用高级 ACL 配置防火墙组网图



配置思路

采用如下的配置思路：

1. 为企业内部网络和外部网络配置不同的安全区域。
2. 配置安全域间，在安全域间使能防火墙功能。
3. 配置不同的高级ACL，对可以访问内部服务器的外部网络用户以及可以访问外部网络的内部服务器进行分类。
4. 在安全域间配置基于高级ACL的包过滤。

操作步骤

步骤1 配置安全区域

为企业内部网络配置安全区域。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] firewall zone company
[Router-zone-company] priority 12
[Router-zone-company] quit
```

配置接口加入VLAN，并配置VLANIF接口的IP地址，将接口VLANIF 100加入安全区域company。

```
[Router] vlan batch 100
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type access
[Router-Ethernet2/0/0] port default vlan 100
[Router-Ethernet2/0/0] quit
[Router] interface vlanif 100
[Router-Vlanif100] ip address 10.10.10.1 255.255.255.0
[Router-Vlanif100] zone company
[Router-Vlanif100] quit
```

为外部网络配置安全区域。


```
[Router] firewall zone external
[Router-zone-external] priority 5
[Router-zone-external] quit
```

将接口GigabitEthernet1/0/0加入安全区域external。

```
[Router] interface gigabitethernet 1/0/0
[Router-gigabitethernet1/0/0] ip address 10.39.10.8 255.255.255.0
[Router-gigabitethernet1/0/0] zone external
[Router-gigabitethernet1/0/0] quit
```

步骤2 配置安全域间

```
[Router] firewall interzone company external
[Router-interzone-company-external] firewall enable
[Router-interzone-company-external] quit
```

步骤3 配置ACL 3001

创建ACL 3001。

```
[Router] acl 3001
```

配置允许特定用户从外部网络可以访问内部服务器。

```
[Router-acl-adv-3001] rule permit tcp source 1.2.3.4 0.0.0.0 destination 10.10.10.5 0.0.0.0
[Router-acl-adv-3001] rule permit tcp source 1.2.3.4 0.0.0.0 destination 10.10.10.6 0.0.0.0
[Router-acl-adv-3001] rule permit tcp source 1.2.3.4 0.0.0.0 destination 10.10.10.7 0.0.0.0
```

配置其他用户不能从外部网络访问企业内部的任何主机。

```
[Router-acl-adv-3001] rule deny ip
[Router-acl-adv-3001] quit
```

步骤4 配置ACL 3002

创建ACL 3002。

```
[Router] acl 3002
```

配置允许内部服务器访问外部网络。

```
[Router-acl-adv-3002] rule permit ip source 10.10.10.5 0.0.0.0
[Router-acl-adv-3002] rule permit ip source 10.10.10.6 0.0.0.0
[Router-acl-adv-3002] rule permit ip source 10.10.10.7 0.0.0.0
```

配置网络内部的其他用户不能访问外部网络。

```
[Router-acl-adv-3002] rule deny ip
[Router-acl-adv-3002] quit
```

步骤5 在安全域间配置基于高级ACL的包过滤

```
[Router] firewall interzone company external
[Router-interzone-company-external] packet-filter 3001 inbound
[Router-interzone-company-external] packet-filter 3002 outbound
[Router-interzone-company-external] quit
```

步骤6 验证配置结果

配置成功后，仅特定主机（1.2.3.4）可以访问内部服务器，仅内部服务器可以访问外部网络。

在Router上执行**display firewall interzone [zone-name1 zone-name2]**操作，结果如下。

```
[Router] display firewall interzone company external
interzone company external
firewall enable
packet-filter default deny inbound
```

```
packet-filter default permit outbound
packet-filter 3001 inbound
packet-filter 3002 outbound
```

----结束

配置文件

Router的配置文件

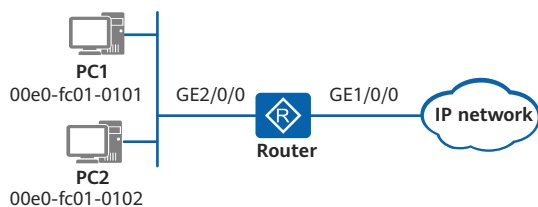
```
#
sysname Router
#
vlan batch 100
#
acl number 3001
rule 5 permit tcp source 1.2.3.4 0 destination 10.10.10.5 0
rule 10 permit tcp source 1.2.3.4 0 destination 10.10.10.6 0
rule 15 permit tcp source 1.2.3.4 0 destination 10.10.10.7 0
rule 20 deny ip
acl number 3002
rule 5 permit ip source 10.10.10.5 0
rule 10 permit ip source 10.10.10.6 0
rule 15 permit ip source 10.10.10.7 0
rule 20 deny ip
#
interface Vlanif100
ip address 10.10.10.1 255.255.255.0
zone company
#
firewall zone company
priority 12
#
firewall zone external
priority 5
#
firewall interzone company external
firewall enable
packet-filter 3001 inbound
packet-filter 3002 outbound
#
interface Ethernet2/0/0
port link-type access
port default vlan 100
#
interface GigabitEthernet1/0/0
ip address 10.39.10.8 255.255.255.0
zone external
#
return
```

5.9.10 使用二层 ACL 禁止特定用户上网示例

组网需求

如图5-21所示，Router作为网关设备，下挂用户PC。管理员发现PC1（MAC地址为00e0-fc01-0101）用户是非法用户，要求禁止该用户上网。

图 5-21 使用二层 ACL 禁止特定用户上网示例组网图



配置思路

采用如下的思路在Router上进行配置：

1. 配置二层ACL和基于ACL的流分类，使设备对MAC地址为00e0-fc01-0101的报文进行过滤，从而禁止该地址对应的用户上网。

2. 配置流行为，拒绝匹配上ACL的报文通过。
3. 配置并应用流策略，使ACL和流行为生效。

操作步骤

步骤1 配置ACL

配置符合要求的二层ACL。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] acl 4000
[Router-acl-L2-4000] rule deny source-mac 00e0-fc01-0101 ffff-ffff-ffff
[Router-acl-L2-4000] quit
```

步骤2 配置基于ACL的流分类

配置流分类tc1，对匹配ACL 4000的报文进行分类。

```
[Router] traffic classifier tc1
[Router-classifier-tc1] if-match acl 4000
[Router-classifier-tc1] quit
```

步骤3 配置流行为

配置流行为tb1，动作为拒绝报文通过。

```
[Router] traffic behavior tb1
[Router-behavior-tb1] deny
[Router-behavior-tb1] quit
```

步骤4 配置流策略

配置流策略tp1，将流分类tc1与流行为tb1关联。

```
[Router] traffic policy tp1
[Router-trafficpolicy-tp1] classifier tc1 behavior tb1
[Router-trafficpolicy-tp1] quit
```

步骤5 应用流策略

由于PC1的报文从接口GE2/0/0进入Router并流向Internet，所以可以在接口GE2/0/0的入方向应用流策略tp1。

```
[Router] interface gigabitethernet 2/0/0
[Router-GigabitEthernet2/0/0] traffic-policy tp1 inbound
[Router-GigabitEthernet2/0/0] quit
```

步骤6 验证配置结果

查看ACL规则的配置信息。

```
[Router] display acl 4000
L2 ACL 4000, 1 rule
Acl's step is 5
rule 5 deny source-mac 00e0-fc01-0101
```

查看流分类的配置信息。

```
[Router] display traffic classifier user-defined
User Defined Classifier Information:
Classifier: tc1
Operator: OR
Rule(s) :
if-match acl 4000
```

查看流策略的配置信息。

```
[Router] display traffic policy user-defined tp1
```

```
User Defined Traffic Policy Information:
```

```
Policy: tp1
```

```
Classifier: tc1
```

```
Operator: OR
```

```
Behavior: tb1
```

```
Deny
```

```
Precedence: 5
```

源MAC地址是00e0-fc01-0101的用户无法上网。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
acl number 4000
rule 5 deny source-mac 00e0-fc01-0101
#
traffic classifier tc1 operator or
if-match acl 4000
#
traffic behavior tb1
deny
#
traffic policy tp1
classifier tc1 behavior tb1 precedence 5
#
interface GigabitEthernet2/0/0
traffic-policy tp1 inbound
#
return
```

相关资料

视频：

- [限制指定IP不能上网](#)
- [通过配置MAC地址过滤，限制指定用户上网](#)

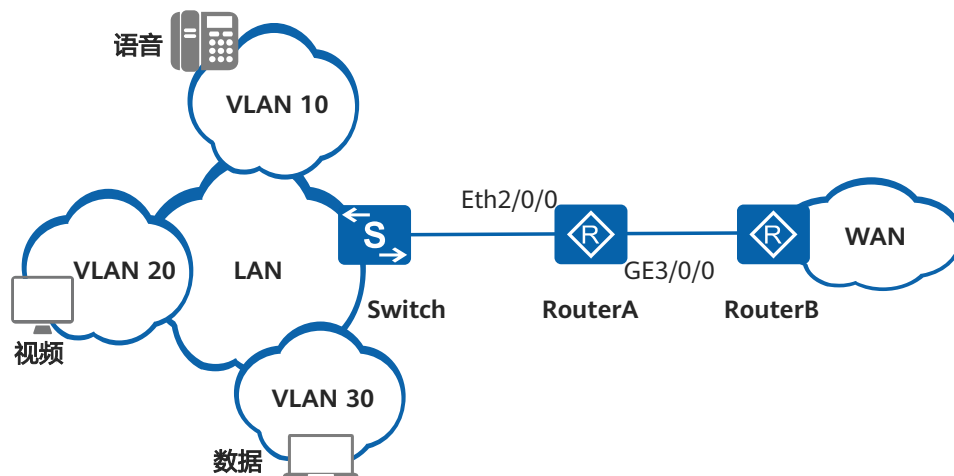
5.9.11 在 QoS 中使用二层 ACL 实施流量监管示例

组网需求

如图5-22所示，企业网内部LAN侧的语音、视频和数据业务对应的VLAN ID分别为10、20、30，并通过Switch连接到RouterA的Eth2/0/0上，通过RouterA的GE3/0/0接口连接到WAN侧网络。

在RouterA上需要对不同业务的报文分别进行基于流的流量监管，以将各业务流量控制在一个合理的范围之内，保证各业务的带宽要求；并对接口Eth2/0/0入方向的所有流量进行基于接口的流量监管，控制单个企业用户的总流量在一个合理范围之内。

图 5-22 配置流量监管的组网图



配置思路

采用如下的思路配置流量监管：

1. 在RouterA上创建VLAN、VLANIF，并配置各接口，使企业用户能通过RouterA访问WAN侧网络。
2. 在RouterA上配置基于VLAN ID进行流分类的匹配规则。
3. 在RouterA上配置流行为，对来自企业网内部的不同业务报文进行流量监管。
4. 在RouterA上配置流量监管策略，绑定已配置的流行为和流分类，并应用到RouterA与Switch连接的接口入方向上。
5. 在RouterA与Switch连接的接口入方向上配置基于接口的流量监管，对来自该企业网内部的所有报文进行流量监管。

操作步骤

步骤1 创建VLAN并配置各接口

在RouterA上创建VLAN10、VLAN20和VLAN30。

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] vlan batch 10 20 30
```

配置接口Eth2/0/0为Trunk类型端口，并允许VLAN10、VLAN20和VLAN30的报文通过。

```
[RouterA] interface ethernet 2/0/0
[RouterA-Ethernet2/0/0] port link-type trunk
[RouterA-Ethernet2/0/0] port trunk allow-pass vlan 10 20 30
[RouterA-Ethernet2/0/0] quit
```

说明

请配置Switch与RouterA对接的接口为Trunk类型接口，并允许VLAN10、VLAN20和VLAN30的报文通过。

创建VLANIF10、VLANIF20和VLANIF30，并为VLANIF10配置IP地址192.168.1.1/24，并为VLANIF20配置IP地址192.168.2.1/24，为VLANIF30配置IP地址192.168.3.1/24。

```
[RouterA] interface vlanif 10
[RouterA-Vlanif10] ip address 192.168.1.1 24
[RouterA-Vlanif10] quit
[RouterA] interface vlanif 20
[RouterA-Vlanif20] ip address 192.168.2.1 24
[RouterA-Vlanif20] quit
[RouterA] interface vlanif 30
[RouterA-Vlanif30] ip address 192.168.3.1 24
[RouterA-Vlanif30] quit
```

配置GE3/0/0的IP地址为192.168.4.1/24。

```
[RouterA] interface gigabitethernet 3/0/0
[RouterA-GigabitEthernet3/0/0] ip address 192.168.4.1 24
[RouterA-GigabitEthernet3/0/0] quit
```

根据实际情况配置RouterB，确保RouterB与RouterA间路由可达，具体步骤略。

步骤2 配置流分类

在RouterA上创建流分类c1～c3，对来自企业的不同业务流按照其VLAN ID进行分类。

```
[RouterA] traffic classifier c1
[RouterA-classifier-c1] if-match vlan-id 10
[RouterA-classifier-c1] quit
[RouterA] traffic classifier c2
[RouterA-classifier-c2] if-match vlan-id 20
[RouterA-classifier-c2] quit
[RouterA] traffic classifier c3
[RouterA-classifier-c3] if-match vlan-id 30
[RouterA-classifier-c3] quit
```

步骤3 配置流量监管行为

在RouterA上创建流行为b1～b3，对来自企业的不同业务流进行流量监管。

```
[RouterA] traffic behavior b1
[RouterA-behavior-b1] car cir 256
[RouterA-behavior-b1] statistic enable
[RouterA-behavior-b1] quit
[RouterA] traffic behavior b2
[RouterA-behavior-b2] car cir 4000
[RouterA-behavior-b2] statistic enable
[RouterA-behavior-b2] quit
[RouterA] traffic behavior b3
[RouterA-behavior-b3] car cir 2000
[RouterA-behavior-b3] statistic enable
[RouterA-behavior-b3] quit
```

步骤4 配置流量监管策略并应用到接口上

在RouterA上创建流策略p1，将流分类和对应的流行为进行绑定并将流策略应用到接口Eth2/0/0入方向上，对来自企业的不同业务报文进行基于流的流量监管。

```
[RouterA] traffic policy p1
[RouterA-trafficpolicy-p1] classifier c1 behavior b1
[RouterA-trafficpolicy-p1] classifier c2 behavior b2
[RouterA-trafficpolicy-p1] classifier c3 behavior b3
[RouterA-trafficpolicy-p1] quit
[RouterA] interface ethernet 2/0/0
[RouterA-Ethernet2/0/0] traffic-policy p1 inbound
```

步骤5 配置基于接口的流量监管

在RouterA的接口Eth2/0/0入方向上配置基于接口的流量监管，控制单个企业用户的总流量在一个合理范围之内。

```
[RouterA-Ethernet2/0/0] qos car inbound cir 10000
[RouterA-Ethernet2/0/0] quit
```

步骤6 验证配置结果

查看流分类的配置信息。

```
[RouterA] display traffic classifier user-defined
User Defined Classifier Information:
Classifier: c2
Operator: OR
Rule(s) :
  if-match vlan-id 20
Classifier: c3
Operator: OR
Rule(s) :
  if-match vlan-id 30
Classifier: c1
Operator: OR
Rule(s) :
  if-match vlan-id 10
```

查看流策略的配置信息。

```
[RouterA] display traffic policy user-defined
User Defined Traffic Policy Information:
Policy: p1
Classifier: c1
Operator: OR
Behavior: b1
Committed Access Rate:
  CIR 256 (Kbps), PIR 0 (Kbps), CBS 48128 (byte), PBS 80128 (byte)
Color Mode: color Blind
Conform Action: pass
Yellow Action: pass
Exceed Action: discard
statistic: enable
Precedence: 5

Classifier: c2
Operator: OR
Behavior: b2
Committed Access Rate:
  CIR 4000 (Kbps), PIR 0 (Kbps), CBS 752000 (byte), PBS 1252000 (byte)
Color Mode: color Blind
Conform Action: pass
Yellow Action: pass
Exceed Action: discard
statistic: enable
Precedence: 10

Classifier: c3
Operator: OR
Behavior: b3
Committed Access Rate:
  CIR 2000 (Kbps), PIR 0 (Kbps), CBS 376000 (byte), PBS 626000 (byte)
Color Mode: color Blind
Conform Action: pass
Yellow Action: pass
Exceed Action: discard
statistic: enable
Precedence: 15
```

查看在接口上应用的流策略信息。

[RouterA] **display traffic policy statistics interface ethernet 2/0/0 inbound**

Interface: Ethernet2/0/0		
Traffic policy inbound: p1		
Rule number: 3		
Current status: OK!		
Item	Sum(Packets/Bytes)	Rate(pps/bps)

Matched	0/0	0/0
Passed	0/0	0/0
Dropped	0/0	0/0
Filter	0/0	0/0
CAR	0/0	0/0
Queue Matched	0/0	0/0
Enqueued	0/0	0/0
Discarded	0/0	0/0
CAR	0/0	0/0
Green packets	0/0	0/0
Yellow packets	0/0	0/0
Red packets	0/0	0/0

----结束

配置文件

- RouterA的配置文件

```
#
sysname RouterA
#
vlan batch 10 20 30
#
traffic classifier c1 operator or
if-match vlan-id 10
traffic classifier c2 operator or
if-match vlan-id 20
traffic classifier c3 operator or
if-match vlan-id 30
#
traffic behavior b1
car cir 256 cbs 48128 pbs 80128 green pass yellow pass red discard
statistic enable
traffic behavior b2
car cir 4000 cbs 752000 pbs 1252000 green pass yellow pass red discard
statistic enable
traffic behavior b3
car cir 2000 cbs 376000 pbs 626000 green pass yellow pass red discard
statistic enable
#
traffic policy p1
classifier c1 behavior b1 precedence 5
classifier c2 behavior b2 precedence 10
classifier c3 behavior b3 precedence 15
#
interface Vlanif10
ip address 192.168.1.1 255.255.255.0
#
interface Vlanif20
ip address 192.168.2.1 255.255.255.0
#
interface Vlanif30
ip address 192.168.3.1 255.255.255.0
#
interface Ethernet2/0/0
port link-type trunk
port trunk allow-pass vlan 10 20 30
qos car inbound cir 10000
traffic-policy p1 inbound
#
interface GigabitEthernet3/0/0
```

```
ip address 192.168.4.1 255.255.255.0
#
return
```

相关资料

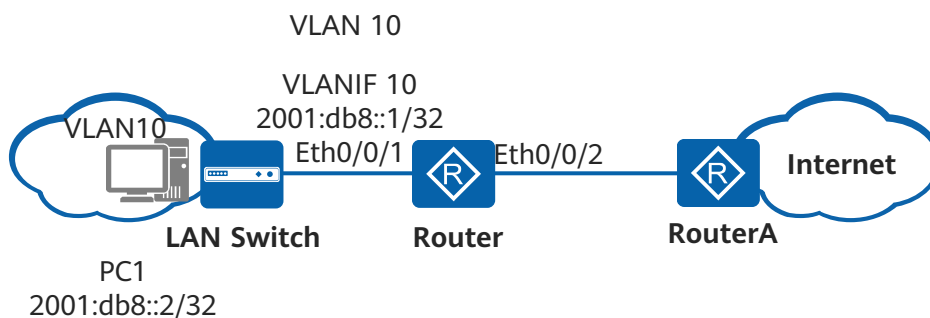
视频：[配置基于接口的限速](#)

5.9.12 使用高级 ACL6 过滤特定 IPv6 报文示例

组网需求

如图5-23所示，Router通过Eth0/0/1接口连接用户。要求Router能对来自用户的特定IPv6报文（源IPv6地址为2001:db8::2/32主机地址、目的IPv6地址为2001:db8::1/32网段地址的IPv6报文）进行过滤，并拒绝该报文通过。

图 5-23 使用高级 ACL6 过滤特定 IPv6 报文示例组网图



配置思路

采用如下思路在Router上进行配置：

1. 配置高级ACL6和基于ACL6的流分类，使设备可以对特定IPv6报文（源IPv6地址为2001:db8::2/32、目的IPv6地址为2001:db8::1/32的IPv6报文）进行过滤。
2. 配置流行为，拒绝匹配上ACL6的报文通过。
3. 配置并应用流策略，使ACL6和流行为生效。

操作步骤

步骤1 使能IPv6转发能力，并配置接口加入VLAN以及VLANIF接口的IPv6地址。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] ipv6
[Router] vlan batch 10
[Router] interface ethernet 0/0/1
[Router-Ethernet0/0/1] port link-type trunk
[Router-Ethernet0/0/1] port trunk allow-pass vlan 10
[Router-Ethernet0/0/1] quit
[Router] interface vlanif 10
[Router-Vlanif10] ipv6 enable
[Router-Vlanif10] ipv6 address 2001:db8::1 32
[Router-Vlanif10] quit
```

步骤2 配置高级ACL6和基于ACL6的流分类，并配置流行为和流策略，再在接口Eth0/0/1的入方向应用流策略，用于拒绝源IPv6地址为2001:db8::2/32、目的IPv6地址为2001:db8::1/32的IPv6报文通过。

```
[Router] acl ipv6 number 3001
[Router-acl6-adv-3001] rule deny ipv6 source 2001:db8::2/32 destination 2001:db8::1/32
[Router-acl6-adv-3001] quit
[Router] traffic classifier class1
[Router-classifier-class1] if-match ipv6 acl 3001
[Router-classifier-class1] quit
[Router] traffic behavior behav1
[Router-behavior-behav1] deny
[Router-behavior-behav1] quit
[Router] traffic policy policy1
[Router-trafficpolicy-policy1] classifier class1 behavior behav1
[Router-trafficpolicy-policy1] quit
[Router] interface ethernet 0/0/1
[Router-Ethernet0/0/1] traffic-policy policy1 inbound
[Router-Ethernet0/0/1] quit
```

步骤3 验证配置结果。

查看ACL6的配置信息。

```
[Router] display acl ipv6 3001

Advanced IPv6 ACL 3001, 1 rule
Acl's step is 5
rule 5 deny ipv6 source 2001:db8::2/32 destination 2001:db8::1/32
```

查看流分类的配置信息。

```
[Router] display traffic classifier user-defined
User Defined Classifier Information:
Classifier: class1
Operator: OR
Rule(s) :
if-match ipv6 acl 3001
```

查看流策略的配置信息。

```
[Router] display traffic policy user-defined
User Defined Traffic Policy Information:
Policy: policy1
Classifier: class1
Operator: OR
Behavior: behav1
Deny
Precedence: 5
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
acl ipv6 number 3001
rule 5 deny ipv6 source 2001:db8::2/32 destination 2001:db8::1/32
#
ipv6
#
vlan batch 10
#
traffic classifier class1 operator or
```

```
if-match ipv6 acl 3001
#
traffic behavior behav1
deny
#
traffic policy policy1
classifier class1 behavior behav1 precedence 5
#
interface Vlanif10
ipv6 enable
ipv6 address 2001:db8::1/32
#
interface Ethernet0/0/1
port link-type trunk
port trunk allow-pass vlan 10
traffic-policy policy1 inbound
#
return
```

5.10 ACL 常见配置错误

5.10.1 IP 地址通配符掩码配置错误导致业务中断

故障现象

设备上部署流量重定向的流策略后，为了继续增加对某个IP地址的报文的重定向，管理员按照ACL配置原则，在流策略引用的ACL中增加了一条使用该地址作为源IP地址匹配项的规则。由于该规则中的IP地址通配符掩码配置错误，导致BGP协议报文不能上送CPU处理，从而造成设备大部分业务的中断。

操作步骤

步骤1 在新配置规则对应的ACL视图下，执行命令**display this**，查看新配置的ACL规则。

新配置的规则如下：

```
rule 100 permit ip source 10.1.1.3 255.255.255.255
```

可以看到，该规则中的IP地址通配符掩码（255.255.255.255），被配置成了正向掩码而非反向掩码，导致该规则的含义发生变化。实际上，该规则与“rule 100 permit ip”和“rule 100 permit ip source any”的含义相同，均表示设备匹配任意IP地址的报文。

而该ACL被用做流量重定向，并且引用该ACL的流策略被应用在了大量的接口下，因此设备从这些接口收到的BGP协议报文会被重定向到其他接口，而不是正常上送CPU处理，从而导致协议超时，造成大部分业务的中断。

步骤2 在新配置规则对应的ACL视图下，执行命令**rule**，修改新配置的ACL规则中的IP地址通配符掩码。

修改后的规则如下：

```
rule 100 permit ip source 10.1.1.3 0.0.0.0 //IP地址通配符掩码为0.0.0.0，才表示单个主机的IP地址
```

规则修改后，中断的业务会恢复正常，源IP地址为10.1.1.3的报文能被正常的重定向。

----结束

5.10.2 误屏蔽 DNS 服务器地址导致用户无法上网

故障现象

配置ACL限制用户可访问的地址时，误将DNS服务器地址加入到了限制的地址范围内，导致用户访问网站时向DNS服务器发送的查询报文被屏蔽，网站域名得不到解析，从而造成用户无法上网。

操作步骤

步骤1 在系统视图下，执行命令**display acl**，查看ACL规则的配置。

发现设备上配置了如下一条规则：

```
rule 100 deny ip destination 10.102.192.0 0.0.0.255 //禁止访问10.102.192.0/24网段的报文通过
```

由于用户PC上设置的DNS服务器地址是10.102.192.68，属于10.102.192.0/24网段，因此用户向DNS服务器发送的报文也被禁止通过，导致其访问网站的域名得不到解析，从而无法上网。

步骤2 在上述规则对应的ACL视图下，执行命令**rule**，在原规则前增加一条放行DNS服务器地址的规则。

```
rule 99 permit ip destination 10.102.192.68 0 //允许访问DNS服务器地址的报文通过  
rule 100 deny ip destination 10.102.192.0 0.0.0.255 //禁止访问10.102.192.0/24网段的报文通过
```

添加新规则rule 99后，用户发送给DNS服务器地址的报文会先命中rule 99而得到允许通过，从而使用户访问网站的域名能够被DNS服务器正常解析，用户可以正常上网。

----结束

5.10.3 系统时间不正确导致基于时间的 ACL 不生效

故障现象

由于设备的系统时间与现实时间不一致，导致设备上配置的基于时间的ACL不生效。

操作步骤

步骤1 在系统视图下，执行命令**display acl**，查看ACL规则的配置。

发现设备上配置了一条基于时间的ACL规则：

```
rule 10 deny ip source 10.1.1.1 0 time-range time1 //在time1设定的时间范围内，禁止源地址是10.1.1.1的报文通过
```

步骤2 在系统视图下，执行命令**display time-range { all | time-name }**，查看生效时间段**time1**的配置。

显示信息如下：

```
Current time is 14:53:17 8-16-2013 Friday  
  
Time-range: time1 ( Inactive )  
from 00:00 2014/1/1 to 23:59 2014/12/31  
Total time-range number is 1
```

可以看到，时间段time1设定的范围是2014年1月1日零点开始到2014年12月31日23：59分结束，并且设备上的系统时间是2013年的8月16日14:53:17秒。由于当前的实际日期是2014年8月16日，并且设备上设置的系统时间不在时间段time1设定的时间范围内，因此引用time1的ACL不生效，源地址是10.1.1.1的报文不会被设备禁止通过。

步骤3 调整系统日期和时间。

- 重新配置设备的当前日期和时间，保证设备时间与现实时间的一致。
在用户视图下，执行命令**clock datetime**。
`clock datetime 14:53:17 2014-08-16` //将日期调整为2014-08-16
- 配置NTP，实现系统时钟的自动同步，使设备与时间可信任的设备（该设备通过网络和权威时钟同步过时钟）上的时间保持一致。
 - a. 在时间可信任的设备上，配置使用本地设备时钟作为NTP主时钟以及NTP主时钟所处的层数。
在系统视图下，执行命令**ntp-service refclock-master**。
`ntp-service refclock-master 2` //层数值越小表示时钟准确度越高
 - b. 在本设备（需同步其他设备时钟的设备）上，配置NTP工作模式，具体配置请参见配置NTP工作模式。

----结束

5.11 ACL FAQ

介绍配置过程中常见的问题，以及解决方法。

5.11.1 ACL 下发主要有哪几种方式？

配置完ACL后，必须在具体的业务模块中应用ACL，才能使ACL正常下发和生效。

最基本的ACL应用方式，是在简化流策略/流策略中应用ACL，使设备能够基于全局或接口下发ACL，实现对转发报文的过滤。此外，ACL还可以应用在Telnet、FTP、路由等模块。

常见的ACL下发方式，如表5-21所示。

表 5-21 常见 ACL 下发方式

业务分类	应用场景	各业务模块的ACL应用方式
对转发的报文进行过滤	基于全局和接口，对转发的报文进行过滤，从而使设备能够进一步对过滤出的报文进行丢弃、修改优先级、重定向等处理。 例如，可以利用ACL，降低P2P下载、网络视频等消耗大量带宽的数据流的服务等级，在网络拥塞时优先丢弃这类流量，减少它们对其他重要流量的影响。	● 简化流策略：请参见《AR300, AR700 配置指南-QoS》中的“基于ACL的简化流策略配置” ● 流策略：请参见《AR300, AR700 配置指南-QoS》中的“MQC配置” ● 包过滤防火墙：请参见《AR300, AR700 配置指南-防火墙配置》中的“6.7 配置包过滤防火墙”

业务分类	应用场景	各业务模块的ACL应用方式
对上送CPU处理的报文进行过滤	对上送CPU的报文进行必要的限制，可以避免CPU处理过多的协议报文造成占用率过高、性能下降。 例如，当发现某用户向设备发送大量的ARP攻击报文，造成设备CPU繁忙，引发系统中断时，可以在本机防攻击策略的黑名单中应用ACL，将该用户加入黑名单，使CPU丢弃该用户发送的报文。	黑名单：请参见“本机防攻击配置”中的“ 8.4.2 配置黑名单 ”
登录控制	对设备的登录权限进行控制，允许合法用户登录，拒绝非法用户登录，从而有效防止未经授权用户的非法接入，保证网络安全性。	• Telnet：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置Telnet服务器功能” • FTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过FTP进行文件操作” • SFTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“通过SFTP进行文件操作” • TFTP：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置设备作为TFTP客户端访问其他设备的文件” • Web登录：请参见《 AR300, AR700 配置指南-基础配置 》中的“配置Web网管参数” • SNMP：请参见《 AR300, AR700 配置指南-网络管理与监控 》中的“（ 可选 ）限制网管对设备的管理权限”（ SNMPv1、SNMPv2c ）和“（ 可选 ）限制网管对设备的管理权限”（ SNMPv3 ）

业务分类	应用场景	各业务模块的ACL应用方式
路由过滤	ACL可以应用在各种动态路由协议中，对路由协议发布、接收的路由信息以及组播组进行过滤。 例如，可以将ACL和路由策略配合使用，禁止设备将某网段路由发给邻居路由器。	• BGP：请参见《 AR300, AR700 配置指南-IP单播路由 》中的“控制BGP路由信息的发布”和“控制BGP路由信息的接收” • IS-IS（ IPv4 ）：请参见《 AR300, AR700 配置指南-IP单播路由 》中的“配置IS-IS发布部分外部路由到IS-IS路由域”和“配置将部分IS-IS路由下发到IP路由表” • OSPF：请参见《 AR300, AR700 配置指南-IP单播路由 》中的“配置OSPF对接收的路由进行过滤”、“配置OSPF对发布的路由进行过滤”和“（可选）配置Helper端GR的会话参数” • RIP：请参见《 AR300, AR700 配置指南-IP单播路由 》中的“配置RIP引入外部路由信息”和“配置RIP对接收的路由进行过滤” • 组播：请参见《 AR300, AR700 配置指南-IP组播 》中的“配置根据源地址过滤IGMP报文”、“配置组播组过滤策略”、“（可选）配置接口加入的组播组范围”和“（可选）配置SSM组策略”

5.11.2 ACL 中的 permit/deny 与 traffic policy 中 behavior 的 permit/deny 之间是什么关系？

ACL与traffic policy（流策略）经常组合使用。traffic policy定义符合ACL的流分类，然后再定义符合流分类的行为，即behavior，例如允许通过、拒绝通过等等。

ACL中的permit/deny与traffic policy中behavior的permit/deny组合有如下四种情况：

表 5-22 ACL 中的 permit/deny 与 traffic policy 中 behavior 的 permit/deny 组合情况

ACL	traffic policy中的 behavior	匹配报文的最终处理结果
permit	permit	permit

ACL	traffic policy中的behavior	匹配报文的最终处理结果
permit	deny	deny
deny	permit	deny
deny	deny	deny

 说明

在流策略模块中，设备默认报文都是permit的，如果只是要求网段之间不能访问，则只需在ACL里配置想要deny的报文的规则即可。如果最后多添加一条rule permit规则，则未命中该规则之前规则的所有报文都会命中此条规则，并且如果流行为behavior被配置为deny，则设备将拒绝所有命中该规则的报文通过，导致全部业务中断。

5.11.3 如何查看 ACL 的生效顺序？

在任意视图下执行命令**display acl { acl-number | name acl-name | all }**、**display acl ipv6 { acl6-number | name acl6-name | all }**或在ACL视图下执行命令**display this**，可以查看ACL规则的生效顺序，如表5-23所示。

表 5-23 ACL 的生效顺序

ACL类型	ACL的生效顺序
config模式的ACL	编号小的规则优先生效
auto模式的ACL	编号小的规则优先生效
config模式的ACL6	编号小的规则优先生效
auto模式的ACL6	排序靠前的规则优先生效，规则按照编号从小到大的顺序进行排序。

 说明

当在流策略中引用ACL并且设备上应用了多个流策略时，如果报文同时匹配上了多个流策略中的ACL规则，则ACL的生效顺序与流策略模块的处理机制相关，具体请参见《 AR300, AR700 配置指南-QoS 》中的介绍。

5.11.4 如何实现单向访问控制？

可以通过以下两种方式实现：

 说明

以下命令行表达方式仅是示意形式，实际配置方法请参考各版本的命令行格式。

- 方式一：流策略

a. 创建高级ACL

在系统视图下，执行命令[acl \[number \] acl-number \[match-order { auto | config } \]](#)，使用编号（3000～3999）创建高级ACL并进入高级ACL视图，或者执行命令[acl name acl-name { advance | acl-number } \[match-order { auto | config } \]](#)，使用名称创建高级ACL并进入高级ACL视图。

b. 配置高级ACL规则

执行命令[rule](#)，配置指定**tcp-flag**参数的高级ACL规则。

假设，要求192.168.1.0/24网段用户可以主动访问192.168.2.0/24网段用户，但反过来192.168.2.0/24网段用户不能主动访问192.168.1.0/24。

由TCP建立连接和关闭连接的过程可知，只有在TCP中间连接过程的报文才会ACK=1或者RST=1。根据这个特点，配置如下两种ACL规则，允许TCP中间连接过程的报文通过，拒绝该网段的其他TCP报文通过，就可以限制192.168.2.0/24网段主动发起的TCP连接。

■ 类型一：配置指定**ack**和**rst**参数的ACL规则

```
rule 5 permit tcp source 192.168.2.0 0.0.0.255 tcp-flag ack //允许ACK=1的TCP报文通过
rule 10 permit tcp source 192.168.2.0 0.0.0.255 tcp-flag rst //允许RST=1的TCP报文通过
rule 15 deny tcp source 192.168.2.0 0.0.0.255 //拒绝该网段的其他TCP报文通过
```

■ 类型二：配置指定**established**参数的ACL规则

```
rule permit tcp source 192.168.2.0 0.0.0.255 tcp-flag established // established表示ACK=1
或者RST=1，表示允许TCP中间连接过程的报文通过
rule deny tcp source 192.168.2.0 0.0.0.255 //拒绝该网段的其他TCP报文通过
```

c. 配置流分类

i. 在系统视图下，执行命令[traffic classifier classifier-name \[operator { and | or } \]](#)，进入流分类视图。

ii. 执行命令[if-match acl { acl-number | acl-name }](#)，配置基于ACL进行分类的匹配规则。

d. 配置流行为

在系统视图下，执行命令[traffic behavior behavior-name](#)，定义流行为并进入流行为视图。

e. 配置流动作。

报文过滤有两种流动作：**deny**或**permit**。其他流动作，请参见《AR300, AR700 配置指南-QoS》中的介绍。

f. 配置流策略

i. 在系统视图下，执行命令[traffic policy policy-name](#)，定义流策略并进入流策略视图。

ii. 执行命令[classifier classifier-name behavior behavior-name](#)，在流策略中为指定的流分类配置所需流行为，即绑定流分类和流行为。

g. 应用流策略

在接口视图下，执行命令[traffic-policy policy-name { inbound | outbound }](#)，应用流策略。

针对上例，需在设备上连接192.168.2.0/24网段的接口入方向上应用流策略。

● 方式二：简化流策略

a. 配置高级ACL和ACL规则（同流策略方式）

b. 应用简化流策略

在接口视图下，执行命令**traffic-filter { inbound | outbound } acl xxx**，应用简化流策略（基于ACL的报文过滤）。

针对流策略方式中的举例，需在设备上连接192.168.2.0/24网段的接口入方向上应用简化流策略。

5.11.5 应用在流策略中的 ACL 不支持对哪些报文进行过滤？

应用在流策略中的ACL不支持对上送CPU处理的协议报文进行过滤，例如：

- VRRP使用的协议报文是目的IP地址为192.168.0.0的组播报文，该报文到达设备后会被上送CPU处理，因此流策略中的ACL对该报文不生效，VRRP组内的成员路由器仍能够协商出主备关系。
- DHCP客户端为了获取合法的动态IP地址，会与服务器之间交互DHCP报文，该报文到达设备后会被上送CPU处理，因此流策略中的ACL对该报文不生效，设备无法阻止一个接口下的用户通过DHCP自动获取IP地址。
- 用户主机Ping本设备时，ICMP报文到达设备后会被上送CPU处理，因此流策略中的ACL对该报文不生效，设备无法阻止用户主机Ping本设备。

对于上送CPU处理的协议报文，可以通过在本机防攻击中的黑名单中应用ACL进行过滤，步骤如下：

1. 在系统视图下，执行命令**cpu-defend policy policy-name**，进入防攻击策略视图。
2. 执行命令**blacklist blacklist-id acl acl-number**，创建黑名单。
3. 执行命令**cpu-defend-policy policy-name [global | slot slot-id]**，应用防攻击策略。

5.11.6 ACL 的 rule 中的 deny/permit 在各个业务模块里的场景是怎样的

ACL的rule中的deny/permit在各个业务模块里的场景不同，具体如下：

- 流策略
 - a. 当ACL的rule配置为**permit**时，系统匹配该规则才执行流行为中的动作，流行为中的动作为**deny**则禁止匹配规则的流量通过，动作为**permit**则允许匹配规则的流量通过。
 - b. 当ACL的rule配置为**deny**时，只要匹配该规则就执行丢弃报文动作，并且流行为中的具体动作不生效（流量统计和流镜像除外）。
 - c. 当ACL里未配置rule时，则应用该ACL的流策略功能不生效。
- 简化流策略
 - a. 当ACL的rule配置为**permit**时，设备执行简化流策略功能中的动作，如允许匹配该规则的报文通过、对匹配ACL规则的报文进行限速等。
 - b. 当ACL的rule配置为**deny**时，如果将ACL应用在简化流策略的报文过滤功能中，设备会拒绝匹配该规则的报文通过。
 - c. 当ACL里未配置rule时，则应用该ACL的简化流策略功能不生效。
- IPSec
 - a. 仅当ACL的rule配置为**permit**时，设备会对匹配该规则的报文进行IPSec保护后再发送该报文。

- b. 当ACL的rule配置为**deny**时，设备不允许匹配ACL规则的报文通过。
 - c. 当ACL未配置rule时，应用该ACL的IPSec功能不生效，即设备直接发送通过接口的报文。
- 防火墙
 - a. 当ACL的rule配置为**permit**时：
 - 如果该ACL应用在**inbound**方向，则允许从优先级低到优先级高的安全区域并且匹配该规则的报文通过。
 - 如果该ACL应用在**outbound**方向，则允许从优先级高到优先级低的安全区域并且匹配该规则的报文通过。
 - b. 当ACL的rule配置为**deny**时：
 - 如果该ACL应用在**inbound**方向，则拒绝从优先级低到优先级高的安全区域且匹配该规则的报文通过。
 - 如果该ACL应用在**outbound**方向，则拒绝从优先级高到优先级低的安全区域且匹配该规则的报文通过。
 - c. 当ACL里未配置rule时：
 - 如果该ACL应用在**inbound**方向，则该ACL不生效，设备会拒绝从优先级低到优先级高的安全区域的所有报文通过。
 - 如果该ACL应用在**outbound**方向，则该ACL不生效，设备会允许从优先级高到优先级低的安全区域的所有报文通过。
- NAT
 - a. 仅当ACL的rule配置为**permit**时，设备允许匹配该规则中指定的源IP地址使用地址池进行地址转换。
 - b. 当ACL的rule配置为**deny**或ACL未配置rule时，应用该ACL的NAT功能不生效，即不允许使用地址池进行地址转换，设备根据目的地址查找路由表转发报文。
- Telnet
 - a. 当ACL的rule配置为**permit**时：
 - 如果该ACL应用在**inbound**方向，则允许匹配该rule规则的其他设备访问本设备。
 - 如果该ACL应用在**outbound**方向，则允许本设备访问匹配该rule规则的其他设备。
 - b. 当ACL的rule配置为**deny**时：
 - 如果该ACL应用在**inbound**方向，则拒绝匹配该rule规则的其他设备访问本设备。
 - 如果该ACL应用在**outbound**方向，则拒绝本设备访问匹配该rule规则的其他设备。
 - c. 当ACL配置了rule，但来自其他设备的报文没有匹配该rule规则时：
 - 如果该ACL应用在**inbound**方向，则拒绝其他设备访问本设备。
 - 如果该ACL应用在**outbound**方向，则拒绝本设备访问其他设备。

- d. 当ACL未配置rule时：
 - 如果该ACL应用在inbound方向，则允许任何其他设备访问本设备。
 - 如果该ACL应用在outbound方向，则允许本设备访问任何其他设备。
- HTTP
 - a. 当ACL的rule配置为**permit**时，则允许指定源IP地址的其他设备与本设备建立HTTP连接。
 - b. 当ACL的rule配置为**deny**时，则拒绝指定源IP地址的其他设备与本设备建立HTTP连接。
 - c. 当ACL未配置rule时，则允许任何其他设备与本设备建立HTTP连接。
- FTP
 - a. 当ACL的rule配置为**permit**时，则允许指定源IP地址的其他设备与本设备建立FTP连接。
 - b. 当ACL的rule配置为**deny**时，则拒绝任何其他设备与本设备建立FTP连接。
 - c. 当ACL配置了rule，但来自其他设备的报文没有匹配该rule规则时，则拒绝其他设备与本设备建立FTP连接。
 - d. 当ACL未配置rule时，则允许任何其他设备与本设备建立FTP连接。
- TFTP
 - a. 当ACL的rule配置为**permit**时，则允许本设备与指定源IP地址的设备建立TFTP连接。
 - b. 当ACL的rule配置为**deny**时，则拒绝本设备与任何其他设备建立TFTP连接。
 - c. 当ACL配置了rule，但来自其他设备的报文没有匹配该rule规则时，则拒绝其他设备与本设备建立TFTP连接。
 - d. 当ACL未配置rule时，则允许本设备与任何其他设备建立TFTP连接。
- SNMP
 - a. 当ACL的rule配置为**permit**时，则允许指定源IP地址的网管访问本设备。
 - b. 当ACL的rule配置为**deny**时，则拒绝其他网管访问本设备。
 - c. 当ACL未配置rule时，则允许任何其他网管访问本设备。
- NTP
 - a. 当ACL的rule配置为**permit**时，则使用**ntp-service access**命令配置的访问控制权限才能生效。
 - b. 当ACL的rule配置为**deny**，则使用**ntp-service access**命令配置的访问控制权限不生效。
 - c. 当ACL未配置rule时，则使用**ntp-service access**命令配置的访问控制权限不生效。

6 防火墙配置

- 6.1 防火墙简介
- 6.2 防火墙原理描述
- 6.3 防火墙应用场景
- 6.4 防火墙配置注意事项
- 6.5 防火墙缺省配置
- 6.6 配置防火墙基本功能
- 6.7 配置包过滤防火墙
- 6.8 配置状态检测防火墙（ASPF）
- 6.9 配置黑名单
- 6.10 配置白名单
- 6.11 配置端口映射
- 6.12 配置攻击防范
- 6.13 配置流量统计和监控
- 6.14 配置防火墙日志
- 6.15 配置虚拟防火墙
- 6.16 配置防火墙主备
- 6.17 维护防火墙
- 6.18 防火墙配置举例
- 6.19 防火墙FAQ

6.1 防火墙简介

定义

防火墙（Firewall）是一种隔离技术，使内网和外网分开，可以防止外部网络用户以非法手段通过外部网络进入内部网络，保护内网免受外部非法用户的侵入。

目的

在大厦构造中，防火墙被设计用来防止火从大厦的一部分传播到另一部分。网络中的防火墙有类似的作用：

- 防止因特网的危险传播到私有网络。
- 在网络内部保护大型机和重要的资源（如数据）。
- 控制内部网络的用户对外部网络的访问。

6.2 防火墙原理描述

6.2.1 安全域

安全域是防火墙功能实现的基础，防火墙的安全域包括安全区域和安全域间。

安全区域

在防火墙中，安全区域（Security Zone），简称为区域（zone），是一个或多个接口的组合，这些接口所包含的用户具有相同的安全属性。每个安全区域具有全局唯一的安全优先级。

设备认为在同一安全区域内部发生的数据流动是可信的，不需要实施任何安全策略。只有当不同安全区域之间发生数据流动时，才会触发防火墙的安全检查，并实施相应的安全策略。

安全域间

任何两个安全区域都构成一个安全域间（Interzone），并具有单独的安全域间视图，大部分的防火墙配置都在安全域间视图下配置。

例如：配置了安全区域zone1和zone2，则在zone1和zone2的安全域间视图中，可以配置ACL包过滤功能，表示对zone1和zone2之间发生的数据流动实施ACL包过滤。

在安全域间使能防火墙功能后，当高优先级的用户访问低优先级区域时，防火墙会记录报文的IP、VPN等信息，生成一个流表。当报文返回时，设备会查看报文的IP、VPN等信息，因为流表里记录有发出报文的信息，所以有对应的表项，返回的报文能通过。低优先级的用户访问高优先级用户时，默认是不允许访问的。因此，把内网设置为高优先级区域，外网设置为低优先级区域，内网用户可以主动访问外网，外网用户则不能主动访问内网。

基于安全域的防火墙的优点

传统的交换机/路由器的策略配置通常都是围绕报文入接口、出接口展开的，随着防火墙的不断发展，已经逐渐摆脱了只连接外网和内网的角色，出现了内网/外网/DMZ

（Demilitarized Zone）的模式。在这种组网环境中，传统基于接口的策略配置方式给网络管理员带来了极大的负担，安全策略的维护工作量成倍增加，从而也增加了因为配置引入安全风险的概率。

除了复杂的基于接口的安全策略配置，某些防火墙支持全局的策略配置，全局策略配置的缺点是配置粒度过粗，一台设备只能配置同样的安全策略，满足不了用户在不同安全区域或者不同接口上实施不同安全策略的要求，使用上具有明显的局限性。

与基于接口和基于全局的配置相比，基于安全域的防火墙支持基于安全区域的配置方式，通过将接口加入安全区域并在安全区域间配置安全策略，既降低了网络管理员配置负担，又能满足复杂组网情况下针对安全区域实施不同攻击防范策略的要求。

6.2.2 防火墙工作模式

为了增加防火墙组网的灵活性，设备不再定义整个设备的工作模式，而是定义接口的工作模式，接口的工作模式如下。

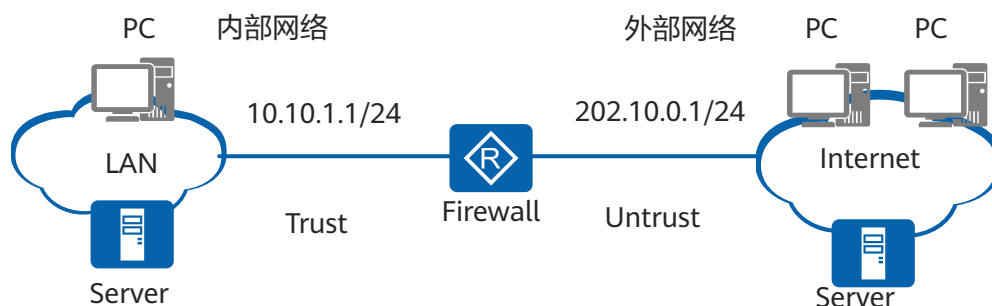
路由模式

当设备位于内部网络和外部网络之间，同时为设备与内部网络、外部网络相连的接口分别配置不同网段的IP地址，并重新规划原有的网络拓扑结构。

如图6-1所示，规划了2个安全区域：Trust区域和Untrust区域，设备的Trust区域接口与公司内部网络相连，Untrust区域接口与外部网络相连。

需要注意的是，Trust区域接口和Untrust区域接口分别处于两个不同的子网中。

图 6-1 路由模式组网图



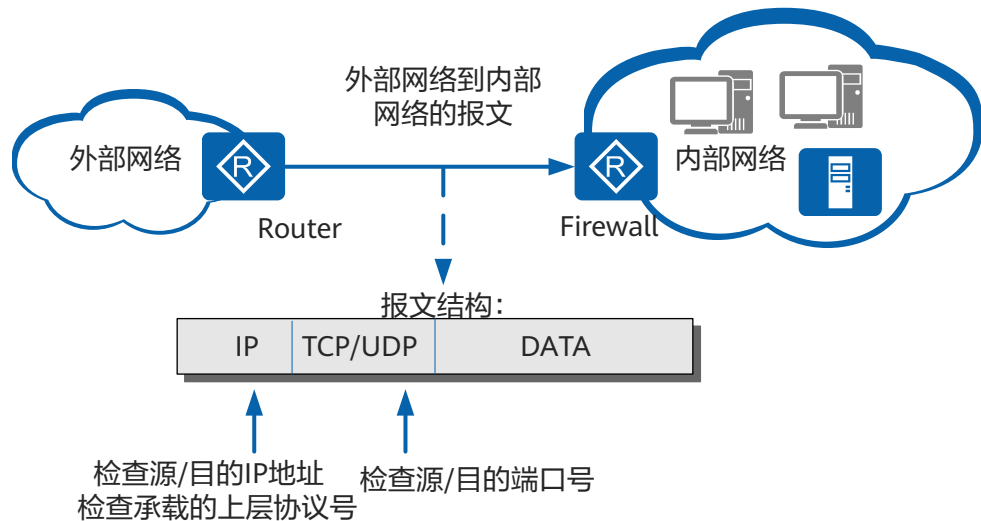
当报文在三层区域的接口间进行转发时，根据报文的IP地址来查找路由表。此时设备表现为一个路由器。但是，与路由器不同的是，设备转发的IP报文还需要进行过滤等相关处理，通过检查会话表或ACL规则以确定是否允许该报文通过。除此之外，防火墙还需要完成其它攻击防范检查。

6.2.3 包过滤防火墙

包过滤防火墙的基本原理是：通过配置ACL实施数据包的过滤。实施过滤主要是基于数据包中的IP层所承载的上层协议的协议号、源/目的IP地址、源/目的端口号和报文传递的方向等信息。

包过滤应用在防火墙中，对需要转发的数据包，先获取数据包的包头信息，然后和设定的ACL规则进行比较，根据比较的结果决定对数据包进行转发或者丢弃。如图6-2所示。

图 6-2 包过滤防火墙



设备对包过滤防火墙的支持

- 普通IP报文过滤：防火墙基于访问控制列表ACL对报文进行检查和过滤。防火墙检查报文的源/目的IP地址、源/目的端口号、协议类型号，根据访问控制列表允许符合条件的报文通过，拒绝不符合匹配条件的报文。防火墙所检查的信息来源于IP、TCP或UDP包头。
- 分片报文过滤：包过滤提供了对分片报文进行检测过滤的支持。包过滤防火墙将识别报文类型，如：非分片报文、首片分片报文、后续分片报文，对所有类型的报文都做过滤。对于首片分片报文，设备根据报文的三层信息及四层信息，与ACL规则进行匹配，如果允许通过，则记录首片分片报文的状态信息，建立后续分片的匹配信息表。当后续分片报文到达时，防火墙不再进行ACL规则的匹配，而是根据首片分片报文的ACL匹配结果进行转发。另外，对于不匹配ACL规则的报文，防火墙还可以配置缺省处理方式。

6.2.4 状态检测防火墙

包过滤防火墙属于静态防火墙，目前存在的问题如下：

- 对于多通道的应用层协议（如FTP、SIP等），部分安全策略配置无法预知。
- 无法检测某些来自传输层和应用层的攻击行为（如TCP SYN、Java Applets等）。
- 无法识别来自网络中伪造的ICMP差错报文，从而无法避免ICMP的恶意攻击。
- 对于TCP连接均要求其首报文为SYN报文，非SYN报文的TCP首包将被丢弃。在这种处理方式下，当设备首次加入网络时，网络中原有TCP连接的非首包在经过新加入的防火墙设备时均被丢弃，这会中断已有的连接。

因此，提出了状态检测防火墙——ASPF（Application Specific Packet Filter）的概念。ASPF能够实现的检测有：

- 应用层协议检测，包括FTP、HTTP、SIP和RTSP检测；
- 传输层协议检测，包括TCP和UDP检测。

ASPF 的功能

ASPF的主要功能如下：

- 能够检查应用层协议信息，如报文的协议类型和端口号等信息，并且监控基于连接的应用层协议状态。对于所有连接，每一个连接状态信息都将被ASPF维护，并用于动态地决定数据包是否被允许通过防火墙进入内部网络，以阻止恶意的入侵。
- 能够检测传输层协议信息（即通用TCP/UDP检测），能够根据源、目的地址及端口号决定TCP或UDP报文是否可以通过防火墙进入内部网络。

ASPF的其它功能有：

- ASPF不仅能够根据连接的状态对报文进行过滤，还能够对应用层报文的内容加以检测。
- 支持TCP连接首包检测。
- 支持ICMP差错报文检测。正常ICMP差错报文中均携带有本报文对应连接的相关信息，根据这些信息可以匹配到相应的连接。如果匹配失败，则根据当前配置决定是否丢弃该ICMP报文。

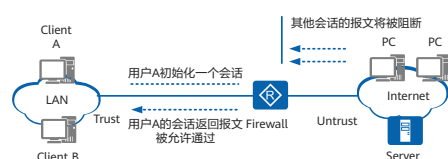
在网络边界，ASPF和包过滤防火墙协同工作，能够为企业内部网络提供更全面的、更符合实际需求的安全策略。

ASPF 基本概念

- 单通道协议
单通道协议：从会话建立到删除的全过程中，只有一个通道参与数据交互，如HTTP。
- 多通道协议
多通道协议：包含一个控制通道和若干其它控制或数据通道，即控制信息的交互和数据的传送是在不同的通道上完成的，如FTP、RTSP。

应用层协议检测基本原理

图 6-3 应用层协议检测基本原理示意图



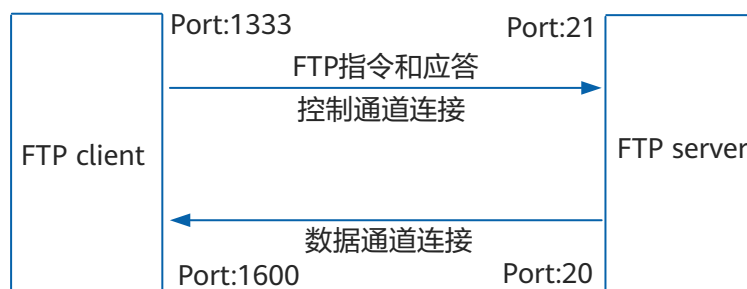
如图6-3所示，为了保护内部网络，一般情况下需要在设备上配置访问控制列表，以允许内部网的主机访问外部网络，同时拒绝外部网络的主机访问内部网络。但访问控制列表会将用户发起连接后返回的报文过滤掉，导致连接无法正常建立。

当在设备上配置了应用层协议检测后，ASPF可以检测每一个应用层的会话，并创建一个状态表项和一个临时访问控制列表（Temporary Access Control List，TACL）：

1. 状态表项在ASPF检测到第一个向外发送的报文时创建，用于维护一次会话中某一时刻会话所处的状态，并检测会话状态的转换是否正确。
2. 临时访问控制列表的表项在创建状态表项的同时创建，会话结束后删除，它相当于一个扩展ACL的permit项。TACL主要用于匹配一个会话中的所有返回的报文，可以为某一应用返回的报文在防火墙的外部接口上建立一个临时的返回通道。

下面以FTP检测为例说明多通道应用层协议检测的过程。

图 6-4 FTP 检测过程示意图



如图6-4所示，FTP连接的建立过程如下：假设FTP client以1333端口向FTP server的21端口发起FTP控制通道的连接，通过协商决定由FTP server的20端口向FTP Client的1600端口发起数据通道的连接，数据传输超时或结束后连接删除。

FTP检测在FTP连接建立到拆除过程中的处理如下：

1. 检查从出接口上向外发送的IP报文，确认为基于TCP的FTP报文。
2. 检查端口号确认连接为控制连接，建立返回报文的TACL和状态表项。
3. 检查FTP控制连接报文，解析FTP指令，根据指令更新状态表项。如果包含数据通道建立指令，则创建数据连接的TACL；对于数据连接，不进行状态检测。
4. 对于返回报文，根据协议类型做相应匹配检查，检查将根据相应协议的状态表项和TACL决定报文是否允许通过。
5. FTP连接删除时，状态表及TACL随之删除。

单通道应用层协议（如HTTP）的检测过程比较简单，当发起连接时建立TACL，连接删除时随之删除TACL即可。

传输层协议检测基本原理

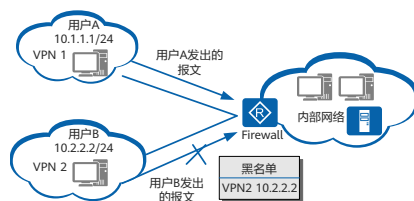
这里的传输层协议检测是指通用TCP/UDP检测。通用TCP/UDP检测与应用层协议检测不同，是对报文的传输层信息进行的检测，如源、目的地址及端口号等。通用TCP/UDP检测要求返回到ASPF外部接口的报文要与前面从ASPF外部接口发出去的报文完全匹配，即源、目的地址及端口号恰好对应，否则返回的报文将被阻塞。因此对于FTP这样的多通道应用层协议，在不配置应用层检测而直接配置TCP检测的情况下会导致数据连接无法建立。

6.2.5 黑名单

黑名单，指根据报文的源VPN和源IP地址进行过滤的一种方式。同ACL相比，由于进行匹配的域非常简单，可以以很高的速度实现报文的过滤，从而有效地将特定IP地址发送来的报文屏蔽，同时支持用户静态配置黑名单和防火墙动态生成黑名单。

如图6-5所示，用户B的IP地址已经在黑名单中，从用户B发出的所有报文都会被防火墙丢弃。

图 6-5 黑名单



设备对黑名单的支持

除了用户可以静态配置黑名单外，当设备发现特定IP地址在进行IP扫描攻击或端口扫描攻击时，会将发起攻击的IP主动插入到黑名单中。如果黑名单已使能的话，在此后的一定时间内，来自这个IP地址的任何报文，都可以被黑名单过滤掉。

用户可以配置静态和动态黑名单的老化时间。

无论命中了黑名单的数据包是否为ACL规则允许的访问，防火墙对此类数据包予以丢弃。

用户可以将黑名单配置信息导出到文件中，也可以通过文件导入黑名单配置。

6.2.6 白名单

在防火墙上加入白名单的主机不会再被加入动态和静态黑名单，使用源VPN和IP地址来表示一个白名单项。

白名单主要用在网络上的特定设备发出的合法业务报文具备IP扫描攻击和端口扫描攻击特性的场合，防止该特定设备被防火墙加入黑名单。

白名单只有静态的。

白名单的特点

如果用户将某个主机的VPN和IP地址加入防火墙白名单，防火墙就不会对该主机发出的报文进行IP扫描攻击和端口扫描攻击检查，也不会将其IP地址生成动态黑名单，也不允许用户将白名单主机添加到静态黑名单中。

设备对白名单的支持

当设备收到一个报文后，就会检查是否是来自于白名单项的报文。如果是，设备对该报文就不会进行IP扫描攻击和端口扫描攻击检查，也不会将源IP生成动态黑名单，但是其他安全过滤功能，比如ACL包过滤、ASPF、流量统计和监控等，还是要进行，以达到防火墙的最大安全过滤效果。

用户可以配置白名单的老化时间。

用户可以将白名单配置信息导出到文件中，也可以通过文件导入白名单配置。

6.2.7 端口映射

应用层协议通常使用知名端口号进行通信。端口映射允许用户对不同的应用层协议定义一组新的端口号，还可以指定使用非知名端口的主机范围。

端口映射只有和ASPF、NAT等针对业务敏感的特性联合使用的时候才具有实际意义。例如在一个企业私网中，内部FTP服务器10.10.10.10通过2121端口提供FTP服务。用户通过NAT服务器访问FTP服务器时，只能使用2121做为端口号。由于默认情况下FTP报文的端口号是21，这时FTP服务器无法将21端口的报文识别为FTP应用。在这样的场合则需要使用端口映射功能把2121端口映射成FTP协议，则NAT服务器就把2121端口的报文识别为FTP协议报文转发给FTP服务器，实现用户对FTP服务器的访问。

设备对端口映射的支持都是通过ACL来实现的，只有匹配某条ACL的报文，才会实施端口映射。端口映射使用基本ACL（编号2000～2999）。端口映射在使用ACL过滤报文时，使用报文的目的IP地址去匹配基本ACL规则中配置的IP地址。

如图6-6所示，外部PC通过Router访问内部WWW服务器（端口号为8080），在外部PC的报文通过设备时，命中ACL的报文会进行端口映射，只有目的地址是10.38.2.4的报文才可以通过设备进行端口映射访问WWW服务器。

图 6-6 端口映射示意图



6.2.8 攻击防范

攻击防范是防火墙中一种重要的网络安全功能。它可以检测出多种类型的网络攻击行为，并能够采取相应的措施保护内部网络免受恶意攻击，以保证内部网络及系统的正常运行。

网络攻击的种类

网络攻击一般分为拒绝服务型攻击、扫描窥探攻击和畸形报文攻击三大类：

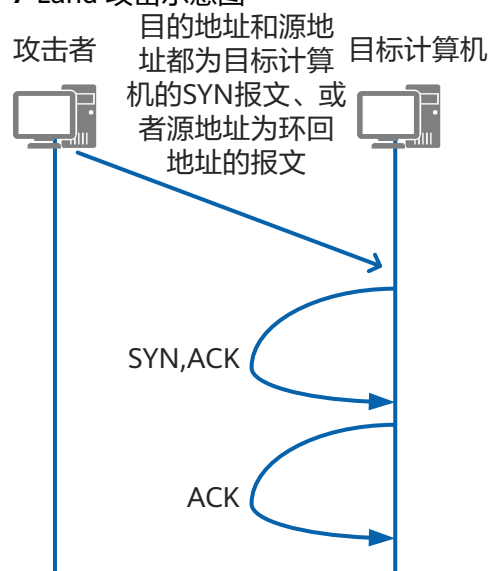
- 拒绝服务型攻击
拒绝服务型DoS（Denial of Service）攻击是使用大量的数据包攻击系统，使系统无法接受正常用户的请求，或者主机挂起不能正常的工作。主要DoS攻击有SYN Flood、Fraggle等。
拒绝服务攻击和其他类型的攻击不同之处在于：攻击者并不是去寻找进入内部网络的入口，而是阻止合法用户访问资源或防火墙。
- 扫描窥探攻击
扫描窥探攻击是利用ping扫描（包括ICMP和TCP）来标识网络上存活着的系统，从而准确地指出潜在的目标。利用TCP和UDP等进行端口扫描，就能检测出操作系统的种类和潜在的服务种类。
攻击者通过扫描窥探就能大致了解目标系统提供的服务种类，为进一步侵入系统做好准备。
- 畸形报文攻击
畸形报文攻击是通过向目标系统发送有缺陷的IP报文，使得目标系统在处理这样的IP包时会出现崩溃，给目标系统带来损失。主要的畸形报文攻击有Ping of Death、Teardrop等。

设备对攻击防范的支持：

Land 攻击

Land攻击，就是把TCP的SYN包的源地址和目的地址都设置为目标计算机的IP地址。这将导致目标计算机向它自己发送SYN-ACK报文，目标计算机又向自己发回ACK报文并创建一个空连接，每一个这样的连接都将保留直到超时。如图6-7所示。

图 6-7 Land 攻击示意图

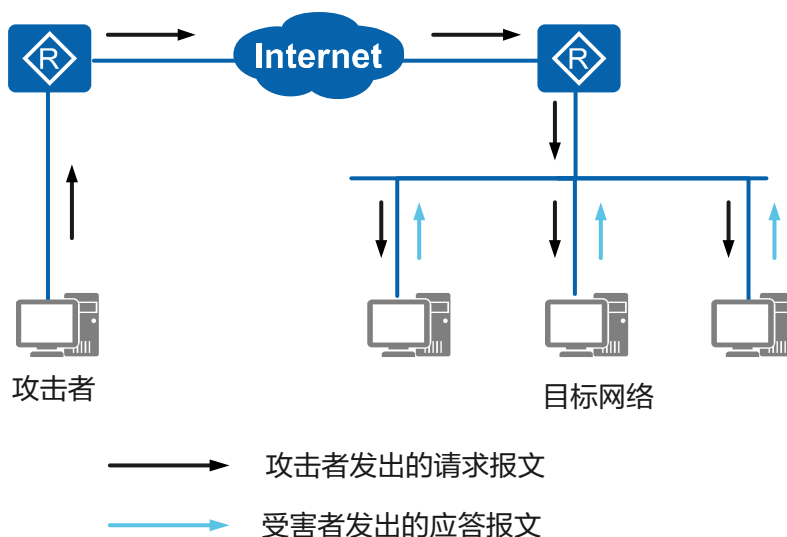


各种类型的主机对Land攻击反应不同，许多UNIX主机将崩溃，Windows NT主机会变得极其缓慢。

Smurf 攻击

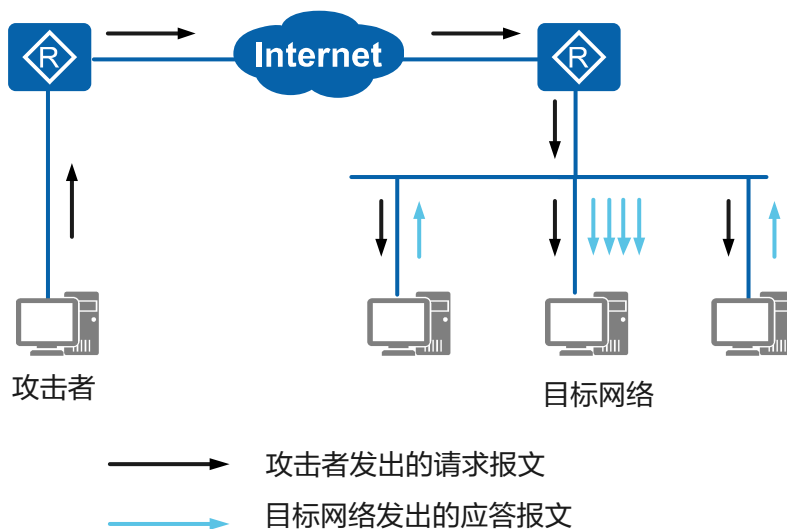
简单的Smurf攻击，用来攻击一个网络。攻击者向目标网络发送ICMP应答请求报文，该报文的源地址设置为目标网络的广播地址，这样，目标网络的所有主机都对此ICMP应答请求作出答复，导致网络阻塞。如图6-8所示。

图 6-8 简单 Smurf 攻击示意图



高级的Smurf攻击，主要用来攻击目标主机。攻击者向目标主机所在的网络发送ICMP应答请求报文，该报文的源地址设置为目标主机的地址，这样，所有的应答报文都将发送给目标主机。最终导致目标主机处理速度缓慢，甚至崩溃。如图6-9所示。

图 6-9 高级 Smurf 攻击示意图



Smurf攻击报文的发送需要一定的流量和持续时间，才能真正构成攻击。理论上讲，目标网络的主机越多，攻击的效果越明显。

WinNuke 攻击

NetBIOS作为一种基本的网络资源访问接口，广泛的应用于文件共享，打印共享，以及不同操作系统之间的数据交换。一般情况下，NetBIOS是运行在LLC2链路协议之上的，是一种基于组播的网络访问接口。在TCP/IP协议栈上实现NetBIOS时，几个常用的TCP/UDP端口如下。

- 139：NetBIOS会话服务的TCP端口。
- 137：NetBIOS名字服务的UDP端口。
- 136：NetBIOS数据报服务的UDP端口。

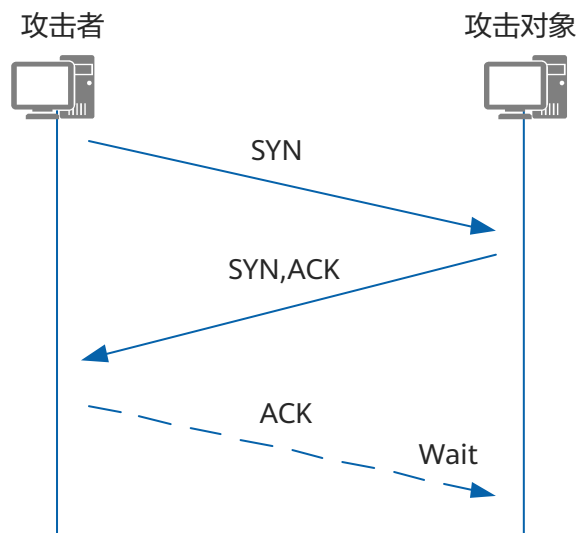
Windows操作系统实现了NetBIOS over TCP/IP功能，并开放了139端口。

WinNuke攻击就是利用了Windows操作系统的一个漏洞，向这个139端口发送一些携带TCP带外（OOB）数据报文，但这些攻击报文与正常携带OOB数据报文不同的是，其指针字段与数据的实际位置不符，即存在重叠，Windows操作系统在处理这些数据的时候，就会崩溃。

SYN Flood 攻击

SYN Flood攻击利用TCP三次握手的一个漏洞向目标计算机发动攻击。攻击者向目标计算机发送TCP连接请求（SYN报文），然后对于目标返回的SYN-ACK报文不作回应。目标计算机如果没有收到攻击者的ACK回应，就会一直等待，形成半连接，直到连接超时才释放。如图6-10所示。

图 6-10 半连接示意图



攻击者利用这种方式发送大量TCP SYN报文，让目标计算机上生成大量的半连接，迫使其大量资源浪费在这些半连接上。目标计算机一旦资源耗尽，就会出现速度极慢、正常的用户不能接入等情况。

攻击者还可以伪造SYN报文，其源地址是伪造的或者不存在的地址，向目标计算机发起攻击。

ICMP Flood 攻击

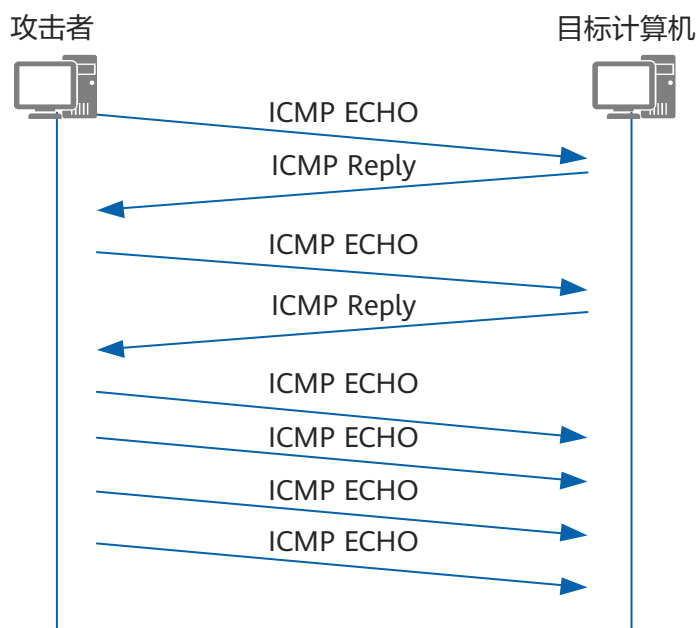
通常情况下，网络管理员会用PING程序对网络进行监控和故障排除，大概过程如下：

1. 源计算机向接收计算机发出ICMP响应请求报文（ICMP ECHO）。
2. 接收计算机接收到ICMP响应请求报文后，会向源计算机回应一个ICMP应答报文（ECHO Reply）。

这个过程是需要CPU处理的，在有些情况下还可能消耗掉大量的资源。

如果攻击者向目标计算机发送大量的ICMP ECHO报文（产生ICMP洪水），则目标计算机忙于处理这些ECHO报文，而无法继续处理其它的数据报文。如图6-11所示。

图 6-11 ICMP Flood 攻击示意图



UDP Flood 攻击

UDP Flood攻击的原理与ICMP Flood攻击类似，攻击者通过发送大量的UDP报文给目标计算机，导致目标计算机忙于处理这些UDP报文而无法继续处理正常的报文。

地址扫描与端口扫描攻击

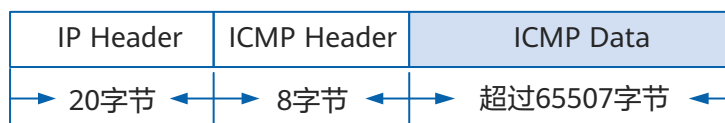
攻击者运用扫描工具探测目标地址和端口，目标地址会对这些探测作出响应，攻击者根据这些响应用来确定哪些目标系统是存活着并且连接在网络上、目标主机开放或者关闭了哪些端口。

Ping of Death 攻击

所谓Ping of Death，就是利用一些尺寸超大的ICMP报文对系统进行的一种攻击。

IP报文的长度字段为16位，这表明一个IP报文的最大长度为65535。对于ICMP回应请求报文，如果数据长度大于65507，就会使ICMP数据 + IP头长度（20）+ ICMP头长度（8）> 65535。对于有些防火墙或系统，在接收到一个这样的报文后，由于处理不当，会造成系统崩溃、死机或重启。如图6-12所示。

图 6-12 ICMP 超大报文示意图



Large-ICMP 攻击

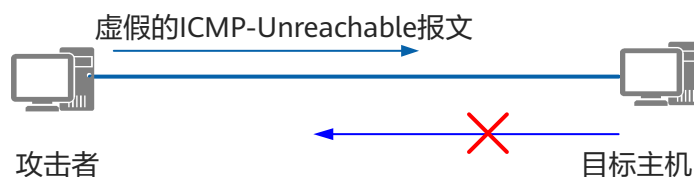
同ping of death类似，Large-ICMP也是利用一些大尺寸的ICMP报文对系统进行的一种攻击，与ping of death不同的是，Large-ICMP报文的长度不会超过IP报文的最大长度65535，但是对一些操作系统也会造成破坏。

需要在防火墙上配置允许通过的ICMP报文的最大长度。

ICMP-Unreachable 攻击

某些系统在收到网络（报文类型字段为3，代码字段为0）或主机（报文类型字段为3，代码字段为1）不可达的ICMP报文后，对于后续发往此目的地的报文直接认为不可达。如图6-13所示。

图 6-13 ICMP-Unreachable 攻击示意图



攻击者利用这种机制，向目标主机发送虚假的ICMP-Unreachable报文，干扰了目标主机的路由信息，影响了报文发送。

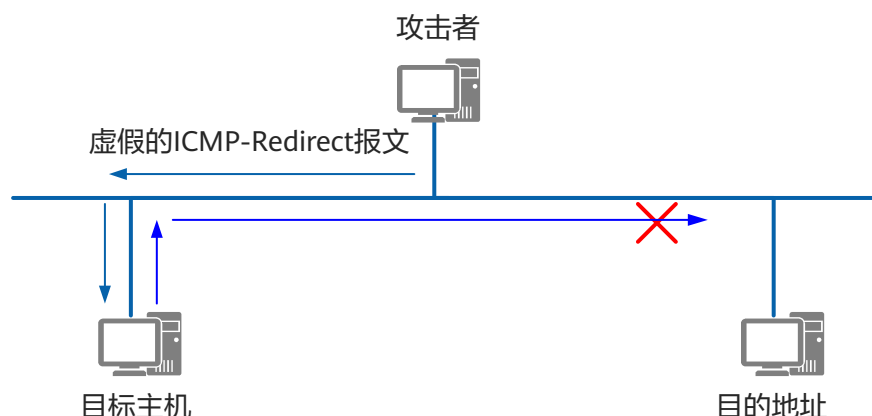
ICMP-Redirect 攻击

ICMP-Redirect攻击和ICMP-Unreachable攻击类似。

网络设备可以向同一个子网的主机发送ICMP重定向报文，请求主机修改路由。

攻击者利用这个原理，跨越网段向另外一个网络的目标主机发送虚假的重定向报文，以改变目标主机的路由表。这种攻击干扰了目标主机的路由信息，影响了报文发送。如图6-14所示。

图 6-14 ICMP-Redirect 攻击示意图



IP-fragment 攻击

IP报文中有几个字段与分片有关：DF（Don't Fragment）位、MF位、Fragment Offset、Length。

如果上述字段的值出现矛盾，而设备处理不当，会对设备造成一定的影响，甚至瘫痪。矛盾的情况有：

- DF位被置位，而MF位同时被置位或Fragment Offset不为0。
- DF位为0，而Fragment Offset + Length > 65535。

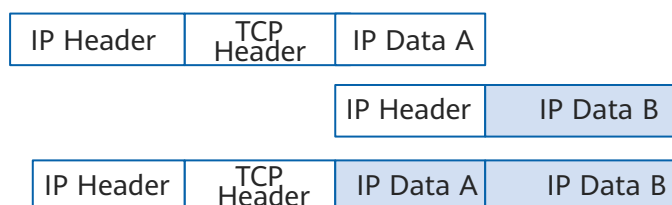
另外，由于分片报文可以增加目的设备缓冲和重组的负担，应直接丢弃目的地址为设备本身的分片报文。

Teardrop 攻击

在网络传输的过程中，如果IP报文的长度超过链路层的MTU（最大传输单元），就会进行分片。在IP报头中有一个偏移字段（OFFSET）和一个分片标志（MF），如果MF标志设置为1，则表明这个IP报文是一个大IP包的片段，其中偏移字段指出了这个片断在整个IP包中的位置。接收端可以根据报文头中的这些信息还原该IP包。

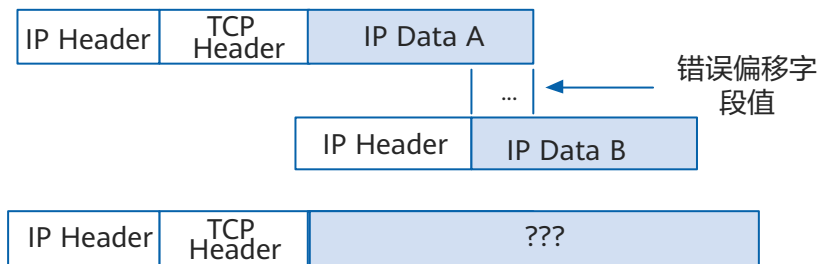
比如，一个较大的报文在MTU较小的链路上传输的时候，被分成了两个IP报文，这两个IP报文将在目的端进行组装，还原为原始的IP报文。如图6-15所示。

图 6-15 正常的分片组装示意图



如果一个攻击者打破这种正常情况，把偏移字段设置成不正确的值，即可能出现重合或断开的情况。某些TCP/IP协议栈在收到类似这种含有重叠偏移的伪造分段时会崩溃，这就是所谓的Teardrop攻击。如图6-16所示。

图 6-16 Teardrop 攻击示意图



Fraggle 攻击

Fraggle攻击的原理与Smurf攻击的原理类似，不过，Fraggle攻击发送的是UDP报文而非ICMP报文。因为发送的是UDP报文，Fraggle攻击可以穿过一些阻止ICMP报文进入的防火墙。

Fraggle攻击利用的原理是：UDP端口7（ECHO）和端口19（Chargen）在收到UDP报文后，都会产生回应。如下：

- UDP的7号端口收到报文后，会象ICMP Echo Reply一样回应收到的内容。
- UDP的19号端口在收到报文后，会产生一串字符流。

这两个UDP端口都会产生大量应答报文，挤占网络带宽。

攻击者可以向目标主机所在的网络发送源地址为被攻击主机、而目的地址为其所在子网的广播地址或子网网络地址的UDP报文，目的端口号为7（ECHO）或19（Chargen）。子网中启用了此功能的每个系统都会向受害主机发送回应报文，从而产生大量的流量，导致受害网络的阻塞或受害主机崩溃。

如果目标主机所在网络上的主机没有启动这些功能，这些主机将产生一个ICMP不可达消息，仍然消耗带宽。也可将源端口改为端口19（Chargen），目的端口为7（ECHO），这样会自动不停地产生回应报文，其危害性更大。

Tracert 攻击

Tracert是利用TTL（Time To Live）为0时返回的ICMP超时报文，和达到目的地时返回的ICMP端口不可达报文来发现报文到达目的地所经过的路径。

攻击者可以利用Tracert窥探网络的结构。对网络造成潜在的危險。

畸形 TCP 报文攻击

畸形TCP报文是通过故意错误设置TCP头中的6个标记位，造成接收方TCP协议栈的处理错误，达到攻击的目的。

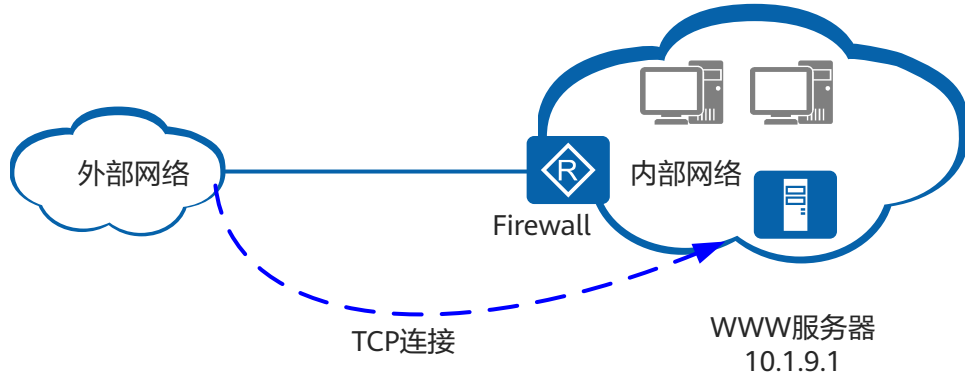
6.2.9 流量统计及监控

防火墙不仅要和数据流量进行监控，还要对内外网络之间的连接发起情况进行检测，进行大量的统计计算与分析。防火墙的统计分析一方面可以通过专门的分析软件对日志信息进行事后分析，另一方面，防火墙系统本身可以完成一部分分析功能，具有一定的实时性。

比如，通过分析外部网络向内部网络发起的TCP/UDP连接数是否超过设定阈值，可以确定是否需要限制该方向发起新连接，或者限制向内部网络某一IP地址发起新连接。

图6-17是防火墙的一个典型应用示例，当启动了外部网络到内部网络的基于IP地址的统计分析功能时，如果外部网络对Web服务器10.1.9.1发起的TCP连接数超过了设定的阈值，将限制外部网络向该服务器发起新连接，直到连接数降到正常范围。

图 6-17 TCP 连接数超限示意图



设备支持的流量统计及监控方法如下：

系统级的流量统计和监控

系统级的流量统计和监控，对系统中所有启用了防火墙功能的安全域间的数据流生效，即设备统计所有安全域间的ICMP、TCP、UDP等连接数。当连接数超过配置阈值时，设备采取限制连接措施，直至连接数降至阈值以下。

基于安全区域的流量统计和监控

基于安全区域的流量统计和监控，对本安全区域和其他安全区域之间的数据流生效，即设备会统计本安全区域和其他所有安全域间建立的TCP、UDP等连接总数。当本安全区域和其他所有安全域间建立的连接总数或者某个方向的连接总数超过配置的阈值时，设备采取限制连接数措施，直至连接数降至阈值以下。

基于 IP 地址的流量统计和监控

基于IP地址的流量统计和监控，用于统计和监控安全区域中单个IP地址所建立的TCP/UDP连接。设备通过分析源IP地址发起或目的地址接收的TCP或UDP连接总数是否超过设定的阈值，可以确定是否需要限制该方向的新的连接的发起，以防止系统受到恶意的攻击或因系统太忙而发生拒绝服务的情况。

当TCP/UDP连接数降至阈值以下后，源IP地址或目的地址可以重新发起或者接受TCP或UDP连接。

6.2.10 防火墙日志

防火墙可以实时记录防火墙的动作和状态（例如实施了某种防火墙措施、检测到某种网络攻击等），并将信息记录到日志中。

对日志内容的分析和归档，能够使管理员检查防火墙的安全风险、何时何人试图违背安全策略、网络攻击的类型，实时的日志记录还可以用来检测正在进行的入侵。

当需要对防火墙的动作和状态进行记录，以便检查防火墙的安全风险、检测网络攻击和入侵等，可以配置防火墙日志功能。

设备对防火墙日志的支持

设备支持以下防火墙日志：

- 黑名单日志
设备在发现有地址扫描、端口扫描等攻击的时候，在黑名单使能的情况下会动态生成黑名单日志。
手动加入的黑名单同样也会生成黑名单日志。
动态生成的黑名单、手动加入的静态黑名单到老化时间之后，会生成解除黑名单日志。
- 攻击日志
设备发现各种攻击类型后，会生成攻击日志，记录攻击类型和参数。
- 流量监控日志
当系统全局、区域出入的会话数超过所配置的连接数阈值上限时，设备会生成流量监控日志，当会话数低于所配置的连接数阈值下限时，设备会生成流量恢复日志。
- 包过滤日志
包过滤功能对报文进行过滤所记录的日志。
- 流日志
设备的流日志是在会话表老化的情况下，封装流日志信息，发送到日志服务器。

6.2.11 虚拟防火墙

近年来小型私有网络不断增加，这些网络一般对应小型企业。此类用户有如下特点：

- 有较强的安全防范需求。
- 经济上无法负担一台专有安全设备。

设备支持从逻辑上划分为多台虚拟防火墙，分别为多个小型私有网络提供独立的安全保障。

每台虚拟防火墙都是VPN（Virtual Private Network）实例（VPN-Instance）、安全实例的综合体。它能够为虚拟防火墙用户提供私有的路由转发平面、安全服务。

VPN 实例

VPN实例为虚拟防火墙用户提供相互隔离的VPN路由，与虚拟防火墙一一对应。这些VPN路由将为各虚拟防火墙接收的报文提供路由支持。

安全实例

安全实例为虚拟防火墙用户提供相互隔离的安全服务，与虚拟防火墙一一对应。这些安全实例具备私有的接口、安全区域、安全域间、ACL和NAT规则，并能为虚拟防火墙用户提供黑名单、包过滤、流量统计和监控、攻击防范、ASPF和NAT等私有的安全服务。

6.2.12 防火墙主备

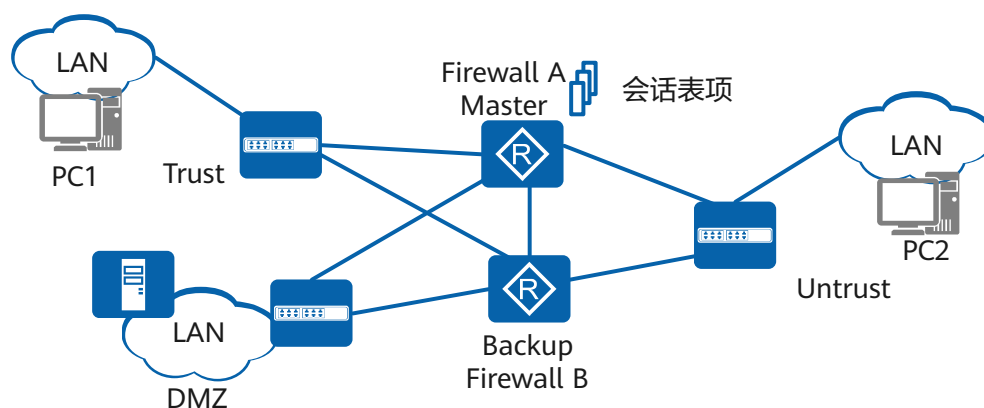
防火墙设备是所有信息流都必须通过的单一点，一旦出现故障所有信息流都会中断。保障信息流不中断至关重要，这就需要解决防火墙设备单点故障问题。

为了解决这一问题，可以由两台防火墙实现冗余路由备份，其中一台为主用（Master）防火墙，另一台为备用（Backup）防火墙。主用和备用防火墙各接口分别连接相应的安全区域。防火墙主备状态由VRRP协议协商确定，通过HSB协议实现防火墙会话表项的同步。

防火墙主备

防火墙是状态检测防火墙，只检查会话流的首包，并动态生成会话表项。对于每一个动态生成的会话连接，防火墙上都有一个会话表项与之对应，会话表项中记录了用户会话的状态信息，后续报文（包括返回报文）只有匹配会话表项才能通过防火墙。

图 6-18 防火墙主备组网图



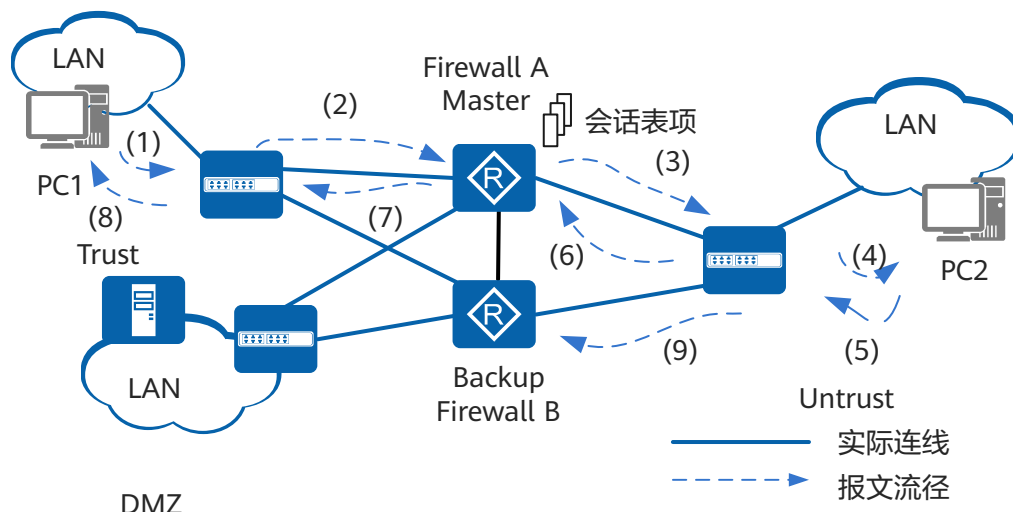
如图6-18所示，Firewall A作为Master设备并承担所有数据传输任务，其上创建了很多动态会话表项；而Firewall B则处于备份状态，没有任何流量经过。

如果Firewall A出现故障或相关链路出现问题，Firewall B将会切换状态变成新的Master，并开始承担传输任务。如果状态切换前，会话表项没有备份到Firewall B，则先前经过Firewall A的所有会话都会因为无法匹配Firewall B的会话表而无法通信，导致业务中断。

为了实现Master防火墙出现故障时能由Backup防火墙平滑地接替工作，在Master和Backup的防火墙之间实时备份会话表和状态信息；当前防火墙主备通过HSB机制实现在Master和Backup防火墙之间进行会话表和状态信息的备份和同步。

防火墙主备的状态要求

图 6-19 防火墙报文路径不一致示意图



防火墙的VRRP状态需要保持一致，这样表示防火墙上和各安全区域相连的若干接口状态相同，即同时处于主用状态或同时处于备用状态。

如图6-19所示，

- 假设Firewall A和Firewall B的VRRP状态一致，即Firewall A的所有接口均为主用状态，Firewall B的所有接口均为备用状态。此时，Trust区域的PC1访问Untrust区域的PC2，报文的转发路线为(1)-(2)-(3)-(4)。Firewall A转发访问报文时，动态生成会话表项。当PC2的返回报文经过(5)-(6)-(7)-(8)到达Firewall A时，则由于能够匹配会话表项，从而顺利返回，通信顺畅。
- 假设Firewall A和Firewall B的VRRP状态不一致，例如，Firewall B与Trust区域相连的接口为备用状态，但与Untrust区域的接口为主用状态，则PC1的报文通过Firewall A设备到达PC2后，在Firewall A上动态生成会话表项。PC2的返回报文通过路线(5)-(9)返回。此时由于Firewall B上没有相应数据流的会话表项，在没有其他报文过滤规则允许通过的情况下，Firewall B将丢弃该报文，导致会话中断。

另外，下行与交换机相连的链路可以通过交换机的SmartLink确保链路的可靠性，同时，在两台防火墙设备间通过直连链路确保下行链路故障时能够通过此链路将相应流量转发到对端防火墙。

说明

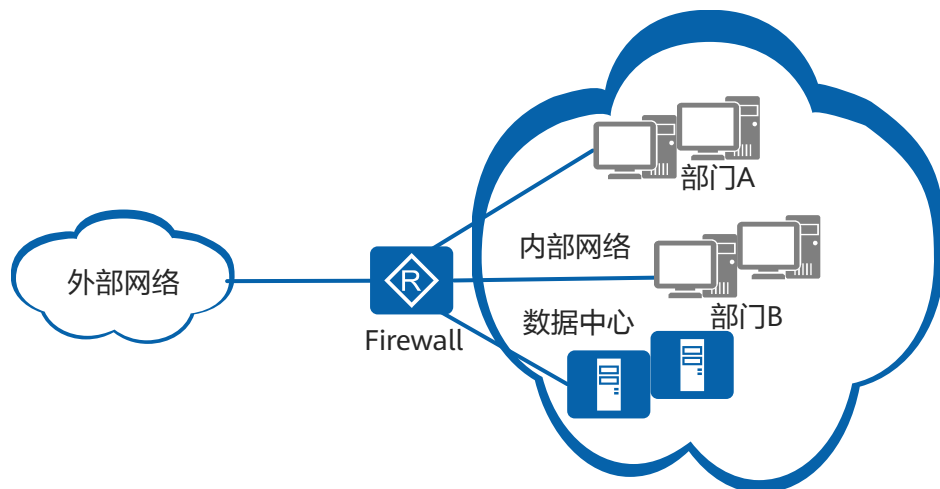
- 防火墙不支持用户配置数据的双机热备份，必须由用户保证备份的两台防火墙上配置数据的一致性。
- 两台互为备份的设备型号必须相同，有相同的内存、CPU以及特性配置，否则不能保证完全备份。
- 两台互为备份的设备的软件版本必须一致。
- 备份接口不能与防火墙业务接口相同，必须使用专用的备份接口，该备份链路不再参与数据转发。
- 不支持非对称路由模式下的防火墙主备，一条流的来回必须经过同一台设备。
- 不支持统计信息的同步，仅支持TCP/UDP协议的会话信息主备。

6.3 防火墙应用场景

6.3.1 防火墙应用在内外网之间

如图6-20所示，防火墙用在内外网络边缘处，防止外部网络对内部网络的入侵。对于使用私有地址的内部网络，可以通过NAT、ALG技术和防火墙技术结合，实现更进一步的安全防护。

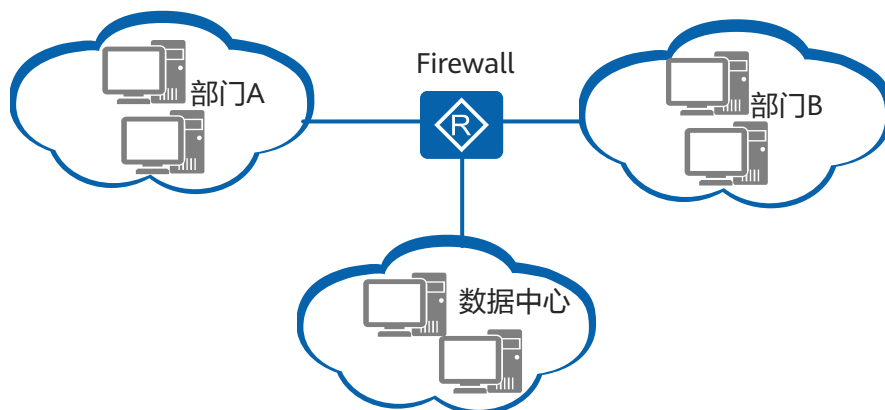
图 6-20 防火墙应用在内外网之间的示意图



6.3.2 防火墙在内部网络中的应用

如图6-21所示，防火墙用于内部网络中，主要是为了防止发自内部的攻击，保障重要数据的安全性。数据中心存储了大量的公司机密。这时，防火墙就需要配置严谨的策略以保护数据中心。

图 6-21 防火墙应用在内部网络的示意图



6.4 防火墙配置注意事项

涉及网元

无需其他网元配合。

License 支持

防火墙是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

6.5 防火墙缺省配置

防火墙的缺省配置如表6-1所示。

表 6-1 防火墙缺省配置

参数	缺省值
防火墙会话表老化时间	各个协议的缺省值不同，具体如下所示： • DNS为120秒 • FTP为120秒 • FTP-DATA为120秒 • HTTP为120秒 • ICMP为20秒 • TCP为600秒 • TCP-PROXY为10秒 • UDP为120秒 • SIP为1800秒 • SIP-MEDIA为120秒 • RTSP为60秒 • RTSP-MEDIA为120秒 • PPTP为600秒 • PPTP-DATA为600秒
包过滤的缺省过滤方式	Outbound方向为允许任何报文通过，Inbound方向为拒绝任何报文通过
Flood类攻击防范的最大连接速率	1000pps
ICMP报文的最大长度	4000字节
地址扫描最大连接速率	4000pps
地址扫描黑名单超时时间	20分钟
端口扫描最大连接速率	4000pps
端口扫描黑名单超时时间	20分钟
系统流量统计和监控的阈值	缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值和下限阈值，可通过命令 display firewall statistics system 查看。 缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值为16384，下限阈值为12288。

参数	缺省值
基于安全区域的流量统计和监控的阈值	缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值和下限阈值，可通过命令 display firewall statistics zone-ip 查看。 缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值为16384，下限阈值为12288。
基于IP地址的流量统计和监控	缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值和下限阈值，可通过命令 display firewall statistics zone-ip 查看。 缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值为16384，下限阈值为12288。

6.6 配置防火墙基本功能

6.6.1 创建安全域并将接口加入安全区域

背景信息

当需要配置防火墙业务时，必须先创建相关的安全区域，根据不同安全区域间的优先级关系来确定安全业务的部署。设备认为在同一安全区域内部发生的数据流动是可信的，不需要实施任何安全策略。只有当不同安全区域之间发生数据流动时，才会触发防火墙的安全检查，并实施相应的安全策略。

创建安全区域必须指定优先级，且指定后不能修改，否则不能进行其他配置。所有安全区域的优先级都不能相同，值越大，则该区域的优先级越高。

需要配置将接口加入安全区域，防火墙才能起作用。

设备会自动创建一个名为Local的安全区域，优先级最高。此安全区域不能被删减，优先级也不能变更，也不能加入接口。如需对上送本设备处理的控制报文应用防火墙功能时，可以使用Local域。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**firewall zone zone-name**，创建安全区域。
缺省情况下，设备没有创建的安全区域。
- 步骤3** 执行命令**priority security-priority**，配置安全区域优先级。
- 步骤4** 执行命令**quit**，进入系统视图。
- 步骤5** 执行命令**interface interface-type interface-number**，进入接口视图。

步骤6 执行命令**zone zone-name**，将接口加入安全区域。

每个安全域可以有多个接口，但每个接口只能加入一个域。

----结束

6.6.2 创建安全域间

背景信息

任何两个安全区域都构成一个安全域间（Interzone），并具有单独的安全域间视图，大部分的防火墙配置都在安全域间视图下配置。配置了防火墙的功能后，设备对这两个安全区域之间发生流动的数据进行检查。

安全域间的数据流动具有方向性，包括入方向（inbound）和出方向（outbound）。

- 入方向：数据由低优先级的安全区域向高优先级的安全区域传输。
- 出方向：数据由高优先级的安全区域向低优先级的安全区域传输。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall interzone zone-name1 zone-name2**，创建安全域间。

创建安全域间必须指定两个已存在的安全区域。

----结束

6.6.3 在安全域间使能防火墙功能

背景信息

只有在安全域间使能防火墙功能后，所配置的所有防火墙功能才能生效。

当安全域间包含local域时，为使该域间防火墙功能生效，必须在系统视图下执行**ip soft-forward enhance enable**命令使能设备的IP增强转发功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall interzone zone-name1 zone-name2**，进入安全域间视图。

其中，*zone-name1*和*zone-name2*已经通过**firewall zone**命令创建完成。

步骤3 执行命令**firewall enable**，使能防火墙功能。

缺省情况下，安全域间的防火墙功能未使能。

----结束

6.6.4 （可选）配置防火墙会话表老化时间

背景信息

设备对于通过防火墙的TCP、UDP、ICMP等协议的数据流都会建立会话表，用于记录协议的连接状态。会话表中含有老化时间，当其中某条记录长时间未被后续报文命中（超过老化时间）时，该会话表项将会被删除。

如果需要修改某协议或目的端口为TCP/UDP协议自定义端口的会话的老化时间时，可以进行防火墙会话表老化时间的配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall-nat session { { dns | ftp | ftp-data | http | icmp | tcp | tcp-proxy | udp | sip | sip-media | rtsp | rtsp-media | pptp | pptp-data } | { tcp | udp } user-define port-number } aging-time time-value**，配置防火墙会话表老化时间。

缺省情况下，各协议的老化时间为：DNS（120秒）、ftp（120秒）、ftp-data（120秒）、HTTP（120秒）、icmp（20秒）、tcp（600秒）、tcp-proxy（10秒）、udp（120秒）、sip（1800秒）、sip-media（120秒）、rtsp（60秒）、rtsp-media（120秒）、pptp（600秒）、pptp-data（600秒）。TCP/UDP协议自定义端口下的会话表项缺省老化时间与对应协议一致。

说明

建议使用缺省的老化时间。

----结束

6.6.5 检查防火墙基本功能的配置结果

操作步骤

- 执行命令**display firewall zone [zone-name] [interface | priority]**，查看安全域的相关信息。
- 执行命令**display firewall interzone [zone-name1 zone-name2]**，查看安全域间的相关信息。
- 执行命令**display firewall-nat session aging-time**，查看防火墙会话表老化时间的信息。

----结束

6.7 配置包过滤防火墙

6.7.1 （可选）配置缺省过滤方式

背景信息

缺省情况下，Outbound方向为允许任何报文通过，Inbound方向为拒绝任何报文通过。

如果域间出或入方向配置了ACL过滤规则，则按照ACL规则进行报文过滤，如果报文不能匹配ACL，则按照默认的规则进行。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall interzone zone-name1 zone-name2**，进入安全域间视图。

步骤3 执行命令**packet-filter default { deny | permit } { inbound | outbound }**，设置包过滤的缺省过滤方式。

说明

更改防火墙安全域间的过滤配置后，建议使用**reset firewall session all**命令清除现有的防火墙会话表项，否则由于更改期间的规则更新，可能会导致部分会话不能按照过滤规则执行正确的过滤动作。

----结束

6.7.2 配置 ACL 包过滤防火墙

背景信息

ACL包过滤可以在两个安全区域之间发生数据流动时，根据ACL规则实施过滤策略。

说明

如果基于物理口建立隧道，当来自隧道的数据流量从Tunnel接口发送或接收，如果需要配置防火墙功能，则需在隧道接口上配置安全域，配置在物理口上功能不生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl [number] acl-number [match-order { config | auto }]**或执行命令**acl ipv6 [number] acl6-number**，创建一个访问控制列表并进入其视图。

说明

ACL包过滤中可以使用的ACL包括基本ACL、高级ACL。

ACL6包过滤中可以使用的ACL6包括基本ACL6、高级ACL6。

步骤3 在基本ACL视图下，执行命令**rule**（基本ACL视图），或在高级ACL视图下，执行命令**rule**（高级ACL视图），或在基本ACL6视图下，执行命令**rule**（基本ACL6视图），或在高级ACL6视图下，执行命令**rule**（高级ACL6视图），配置访问控制规则。

说明

配置ACL6包过滤防火墙业务时，指定rule规则时不支持配置**fragment**参数。

步骤4 执行命令**quit**，返回系统视图。

步骤5 执行命令**firewall interzone zone-name1 zone-name2**，进入安全域间视图。

步骤6 执行命令**packet-filter { acl-number | default { deny | permit } } { inbound | outbound }**或**packet-filter ipv6 acl6-number { inbound | outbound }**，配置ACL包过滤或ACL6包过滤。

在安全域间配置ACL包过滤时，可针对出方向和入方向分别配置。

1. 当ACL的rule配置为**permit**时：
 - 如果该ACL应用在**inbound**方向，则允许从优先级低到优先级高的安全区域并且匹配该规则的报文通过。
 - 如果该ACL应用在**outbound**方向，则允许从优先级高到优先级低的安全区域并且匹配该规则的报文通过。
2. 当ACL的rule配置为**deny**时：
 - 如果该ACL应用在**inbound**方向，则拒绝从优先级低到优先级高的安全区域且匹配该规则的报文通过。
 - 如果该ACL应用在**outbound**方向，则拒绝从优先级高到优先级低的安全区域且匹配该规则的报文通过。
3. 当ACL里未配置rule时：
 - 如果该ACL应用在**inbound**方向，则该ACL不生效，设备会拒绝从优先级低到优先级高的安全区域的所有报文通过。
 - 如果该ACL应用在**outbound**方向，则该ACL不生效，设备会允许从优先级高到优先级低的安全区域的所有报文通过。

在安全域间配置ACL6包过滤时，可针对出方向和入方向分别配置。

当ACL6里未配置rule时：

- 如果该ACL6应用在**inbound**方向，则该ACL6不生效，设备会拒绝从优先级低到优先级高的安全区域的所有报文通过。
- 如果该ACL6应用在**outbound**方向，则该ACL6不生效，设备会允许从优先级高到优先级低的安全区域的所有报文通过。

步骤7 （可选）执行命令**bypass [session-overrun]**，在安全域间配置包过滤bypass功能。

缺省情况下，未在安全域间配置包过滤bypass功能。

----结束

6.7.3 检查包过滤防火墙的配置结果

操作步骤

- 执行命令**display firewall interzone [zone-name1 zone-name2]**，查看包过滤的相关信息。
- 执行命令**display acl acl-number**，查看配置的ACL信息。

----结束

6.8 配置状态检测防火墙（ASPF）

背景信息

ASPF是针对应用层的包过滤，即基于状态的报文过滤，它能够检测试图通过防火墙的应用层协议会话信息，阻止不符合规则的数据报文穿过防火墙。

说明

IPv6防火墙不支持ASPF功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall interzone zone-name1 zone-name2**，进入安全域间视图。

步骤3 执行命令**detect aspf { ftp | rtsp | sip }**，配置ASPF。

应用层协议基本都具有双向交互过程，因此在配置ASPF时，无需配置方向，设备自动对双向的数据报文都进行状态检查。

缺省情况下，安全域间未配置ASPF。

----结束

检查配置结果

- 执行命令**display firewall interzone [zone-name1 zone-name2]**，查看安全域间ASPF的相关信息。

6.9 配置黑名单

6.9.1 使能黑名单

背景信息

黑名单是指根据报文的源IP地址进行过滤的一种方式。同ACL相比，由于进行匹配的字段非常简单，可以以很高的速度实现包过滤，从而有效的将特定IP地址发送来的报文屏蔽。

黑名单最主要的一个特色是可以由防火墙动态地进行添加，当防火墙根据报文的行为特征发现特定IP地址的攻击企图之后，可以主动修改黑名单列表，将这个IP地址发送过来的报文过滤掉。如果需要配置自动添加防火墙黑名单，需要使能地址扫描攻击防范和端口扫描攻击防范功能。

黑名单可以手工配置，也可以由Router在使能攻击防范模块的地址扫描和端口扫描后，当实际针对某个IP地址或端口的连接速率超过设置的值时，Router认为发生了扫描攻击，动态地将该源IP地址加入黑名单表项，以屏蔽该源IP地址发送来的报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 （可选）执行命令**firewall defend ip-sweep enable**，使能地址扫描攻击防范。

步骤3 （可选）执行命令**firewall defend ip-sweep { blacklist-expire-time interval | max-rate rate-value }**，配置地址扫描攻击防范参数。

步骤4 （可选）执行命令**firewall defend port-scan enable**，使能端口扫描攻击防范。

步骤5 （可选）执行命令**firewall defend port-scan { blacklist-expire-time interval | max-rate rate-value }**，配置端口扫描攻击防范参数。

对于扫描类攻击防范，有两个参数：

- 最大连接速率：当实际针对某个IP地址或端口的连接速率超过该值时，设备认为发生了扫描攻击，将该IP地址加入黑名单，禁止建立新连接。
- 黑名单超时时间：黑名单具有超时时间，当IP地址进入黑名单的时间超过超时时间后，设备将其从黑名单中释放，允许建立新连接。

缺省情况下，地址扫描和端口扫描的最大连接速率均为4000pps，黑名单超时时间均为20分钟。

步骤6 执行命令**firewall blacklist enable**，使能黑名单功能。

缺省情况下，防火墙黑名单功能未使能。

----结束

6.9.2 单条配置黑名单表项

背景信息

将某个IP地址加入到防火墙黑名单后，在黑名单表项的有效时间内，防火墙将会过滤从该地址发来的报文。

添加黑名单表项时可以指定IP地址、老化时间和VPN实例。其中老化时间是指IP地址添加到黑名单后生效的时间，当IP地址加入黑名单的时间超过老化时间后，该IP地址从黑名单中释放。如果不指定老化时间，则表示该黑名单表项永远有效。

黑名单表项的添加操作不依赖于黑名单功能是否使能，即使黑名单功能不使能，依然可以添加黑名单表项，只是不会生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall blacklist ip-address [vpn-instance vpn-instance-name] [expire-time minutes]**，添加黑名单表项。

说明

不指定老化时间的黑名单表项会被写入配置文件。指定老化时间的黑名单表项不会被写入配置文件，但可以通过**display firewall blacklist**命令查看。

步骤3 （可选）执行命令**firewall black-white-list save configuration-file configuration-file-name**，可将设备上的黑白名单保存至指定的配置文件，以便于下次加载。

----结束

6.9.3 批量配置黑/白名单表项

背景信息

通过加载黑/白名单配置文件，可以实现快速批量配置黑/白名单功能。批量配置黑/白名单表项，需要预先配置好黑/白名单配置文件。

白名单配置不需要使能，配置的白名单表项直接生效。

黑/白名单配置文件只支持文本格式，格式要求如下：

```
[FirewallBlacklist]      #标识此条目是黑名单
IPAddress =              #黑名单的IP地址，点分十进制格式
VPNName =               #黑名单所属的VPN实例名称，可选配置，不配置即不填。
[FirewallWhitelist]     #标识此条目是白名单
IPAddress =              #白名单的IP地址，点分十进制格式
VPNName =               #白名单所属的VPN实例名称，可选配置，不配置即不填。
```

支持多条配置，但必须逐行进行编辑(行与行之间允许空行)，示例如下：

```
[FirewallBlacklist]
IPAddress = 10.10.10.1
VPNName = vpna
[FirewallBlacklist]
IPAddress = 10.10.10.2
VPNName =

[FirewallWhitelist]
IPAddress = 10.10.10.3
VPNName = vpnb
[FirewallWhitelist]
IPAddress = 10.20.20.1
VPNName =
```

说明

配置文件最多可支持配置50K行。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**firewall black-white-list load configuration-file *configuration-file-name***，加载黑/白名单配置文件。
- 步骤3** 执行命令**firewall blacklist enable**，使能黑名单功能，黑名单功能才会生效。
- 步骤4** （可选）执行命令**firewall black-white-list save configuration-file *configuration-file-name***将设备上的黑/白名单保存至指定的配置文件，以便于下次加载。

----结束

6.9.4 检查黑名单的配置结果

操作步骤

- 执行命令**display firewall blacklist { all | *ip-address* [**vpn-instance** *vpn-instance-name*] | **dynamic** | **static** | **vpn-instance** *vpn-instance-name* }**，查看黑名单的相关信息。
- 执行命令**display firewall blacklist configuration**，查看防火墙黑名单功能是否使能。

----结束

6.10 配置白名单

6.10.1 单条配置白名单表项

背景信息

白名单是根据报文的源IP地址进行过滤，防止特定的IP地址被加入黑名单。在防火墙上加入白名单的主机不会再被加入动态和静态黑名单，使用源VPN和IP地址来表示一个白名单项。

配置白名单可以指定IP地址、老化时间和VPN实例。其中老化时间是指IP地址添加到白名单后生效的时间，当IP地址加入白名单的时间超过老化时间后，该IP地址从白名单中释放。如果不指定老化时间，则表示该白名单表项永远有效。

白名单配置不需要使能，配置的黑/白名单表项直接生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall whitelist ip-address [vpn-instance vpn-instance-name] [expire-time minutes]**，添加白名单表项。

步骤3 （可选）执行命令**firewall black-white-list save configuration-file configuration-file-name**，可将设备上的黑/白名单保存至指定的配置文件，以便于下次加载。

----结束

6.10.2 批量配置黑/白名单表项

背景信息

通过加载黑/白名单配置文件，可以实现快速批量配置黑/白名单功能。批量配置黑/白名单表项，需要预先配置好黑/白名单配置文件。

白名单配置不需要使能，配置的黑/白名单表项直接生效。

黑/白名单配置文件只支持文本格式，格式要求如下：

```
[FirewallBlacklist]      #标识此条目是黑名单
IPAddress =             #黑名单的IP地址，点分十进制格式
VPNName =               #黑名单所属的VPN实例名称，可选配置，不配置即不填。
[FirewallWhitelist]     #标识此条目是白名单
IPAddress =             #白名单的IP地址，点分十进制格式
VPNName =               #白名单所属的VPN实例名称，可选配置，不配置即不填。
```

支持多条配置，但必须逐行进行编辑(行与行之间允许空行)，示例如下：

```
[FirewallBlacklist]
IPAddress = 10.10.10.1
VPNName = vpna
[FirewallBlacklist]
IPAddress = 10.10.10.2
VPNName =

[FirewallWhitelist]
IPAddress = 10.10.10.3
VPNName = vpnb
[FirewallWhitelist]
IPAddress = 10.20.20.1
VPNName =
```

说明

配置文件最多可支持配置50K行。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall black-white-list load configuration-file configuration-file-name**，加载黑/白名单配置文件。

步骤3 执行命令**firewall blacklist enable**，使能黑名单功能，黑名单功能才会生效。

步骤4 （可选）执行命令**firewall black-white-list save configuration-file configuration-file-name**将设备上的黑/白名单保存至指定的配置文件，以便于下次加载。

----结束

6.10.3 检查白名单的配置结果

操作步骤

- 执行**display firewall whitelist { all | ip-address [vpn-instance vpn-instance-name] | vpn-instance vpn-instance-name }**，命令查看白名单的相关信息。
- 执行**display firewall blacklist { { all | ip-address [vpn-instance vpn-instance-name] | dynamic | static | vpn-instance vpn-instance-name }**，命令查看黑名单的相关信息。

----结束

6.11 配置端口映射

背景信息

应用层协议通常使用知名端口号进行通信。端口映射允许用户对不同的应用层协议定义一组新的端口号，使服务器更少地受到针对某种服务的恶意攻击。端口映射只有和ASPF、NAT等针对业务敏感的特性联合使用的时候才具有实际意义。

端口映射基于ACL进行，只有匹配某条ACL的报文，才会实施端口映射。端口映射使用基本ACL（编号2000～2999）。端口映射在使用ACL过滤报文时，使用报文的目的IP地址去匹配基本ACL规则中配置的IP地址。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**port-mapping { dns | ftp | http | sip | rtsp | pptp } port port-number acl acl-number**，配置端口映射。

配置端口映射时，一个协议可以配置多个映射端口；一个端口可以映射为多个协议，但是必须通过ACL进行区分，匹配不同ACL的报文使用不同的映射关系。

说明

端口映射实际上是针对访问某个特定IP地址（例如WWW服务器）的报文进行协议识别，因此在匹配基本ACL规则时，使用报文的目的地址去匹配ACL规则中定义的源IP地址。

----结束

检查配置结果

- 执行命令**display port-mapping [dns | ftp | http | rtsp | sip | port *port-number* | pptp]**，查看端口映射的相关信息。

6.12 配置攻击防范

6.12.1 使能攻击防范

背景信息

用户可以根据需要选择使能不同类型的攻击防范。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 使能攻击防范

- 执行命令**firewall defend all enable**，使能所有类型的攻击防范。
- 执行命令**firewall defend fraggle enable**，使能Fraggle攻击防范。
- 执行命令**firewall defend icmp-flood enable**，使能ICMP Flood攻击防范。
- 执行命令**firewall defend icmp-redirect enable**，使能ICMP Redirect攻击防范。
- 执行命令**firewall defend icmp-unreachable enable**，使能ICMP不可达攻击防范。
- 执行命令**firewall defend ip-fragment enable**，使能IP-Fragment攻击防范。
- 执行命令**firewall defend ip-sweep enable**，使能地址扫描攻击防范。
- 执行命令**firewall defend land enable**，使能Land攻击防范。
- 执行命令**firewall defend large-icmp enable**，使能超大ICMP报文攻击防范。
- 执行命令**firewall defend ping-of-death enable**，使能Ping of Death攻击防范。
- 执行命令**firewall defend port-scan enable**，使能端口扫描攻击防范。
- 执行命令**firewall defend smurf enable**，使能Smurf攻击防范。
- 执行命令**firewall defend syn-flood enable**，使能SYN Flood攻击防范。
- 执行命令**firewall defend tcp-flag enable**，使能TCP标志攻击防范。
- 执行命令**firewall defend teardrop enable**，使能Teardrop攻击防范。
- 执行命令**firewall defend tracert enable**，使能Tracert攻击防范。

- 执行命令**firewall defend udp-flood enable**，使能UDP Flood攻击防范。
- 执行命令**firewall defend winnuke enable**，使能WinNuke攻击防范。
- 缺省情况下，未使能任何类型的攻击防范。

----结束

6.12.2 配置 flood 类攻击防范参数

背景信息

对于Flood类攻击防范，需要指定防范的安全区域或者IP地址，否则防范不能生效。同时还可以指定最大连接速率，当实际的连接速率超过该值时，设备认为发生了攻击，自动采取攻击防范措施。

对于Flood类攻击防范，针对IP地址配置的优先级高于针对安全区域配置的优先级。如果对指定IP地址配置了Flood攻击防范功能，同时也对该IP地址所在安全区域配置了Flood攻击防范功能，则以IP地址所配置的参数为准；如果此时取消针对IP地址的配置，则再以安全区域所配置的参数为准。

以下步骤2～步骤4是并列可选的关系，用户可以根据需要配置不同类型的Flood类攻击防范参数。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall defend icmp-flood { ip ip-address [vpn-instance vpn-instance-name] | zone zone-name } [max-rate rate-value]**，配置ICMP Flood攻击防范参数。

缺省情况下，Flood类攻击防范的最大连接速率均为1000pps。

步骤3 执行命令**firewall defend syn-flood { ip ip-address [vpn-instance vpn-instance-name] | zone zone-name } [max-rate rate-value] [tcp-proxy { auto | off | on }]**，配置SYN Flood攻击防范参数。

缺省情况下，Flood类攻击防范的最大连接速率均为1000pps。

步骤4 执行命令**firewall defend udp-flood { ip ip-address [vpn-instance vpn-instance-name] | zone zone-name } [max-rate rate-value]**，配置UDP Flood攻击防范参数。

缺省情况下，Flood类攻击防范的最大连接速率均为1000pps。

----结束

6.12.3 配置对超大 ICMP 报文的攻击防范

背景信息

对于超大ICMP报文攻击防范参数只有一个，即ICMP报文的最大长度。当实际ICMP报文的长度超过该值时，设备认为发生了超大ICMP报文攻击，将丢弃该报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall defend large-icmp max-length *length***，配置超大ICMP报文攻击防范参数。

缺省情况下，ICMP报文的最大长度为4000字节。

----结束

6.12.4 配置扫描类攻击防范参数

背景信息

对于扫描类攻击防范，有两个参数：

- 最大连接速率：当某个IP访问其他IP或端口的速率超过该值时，设备认为发生了扫描攻击，将该IP地址加入黑名单，禁止建立新连接。
- 黑名单超时时间：黑名单具有超时时间，当IP地址进入黑名单的时间超过超时时间后，设备将其从黑名单中释放，允许建立新连接。

以下步骤2～步骤3是并列可选的关系，用户可以根据需要配置不同类型的扫描类攻击防范参数。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall defend ip-sweep { blacklist-expire-time *interval* | max-rate *rate-value* }**，配置地址扫描攻击防范参数。

步骤3 执行命令**firewall defend port-scan { blacklist-expire-time *interval* | max-rate *rate-value* }**，配置端口扫描攻击防范参数。

缺省情况下，地址扫描和端口扫描的最大连接速率均为4000pps，黑名单超时时间均为20分钟。

----结束

6.12.5 检查攻击防范的配置结果

操作步骤

- 执行命令**display firewall defend { flag | { icmp-flood | syn-flood | udp-flood } [ip [*ip-address* [*vpn-instance* *vpn-instance-name*]] | zone [*zone-name*]] | other-attack-type }**，查看攻击防范的相关信息。

----结束

6.13 配置流量统计和监控

6.13.1 配置系统级流量统计和监控功能

背景信息

系统级的流量统计和监控，对系统中所有启用了防火墙功能的安全域间的数据流生效，设备会统计所有安全域间的ICMP、TCP、UDP等连接数。当连接数超过配置阈值时，采取限制连接措施，直至连接数降至阈值以下。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall statistics system enable**，使能系统流量统计和监控。

缺省情况下，防火墙的系统流量统计和监控功能未使能。

步骤3 （可选）执行命令**firewall statistics system connect-number { frag | icmp | tcp | tcp-proxy | udp } high high-threshold low low-threshold**，配置系统流量统计和监控的阈值。

系统级的流量统计功能可以针对不同的连接类型配置其阈值。例如当TCP的连接数阈值设置为15000时，下限阈值设置为12000时，则当所有安全域间建立的TCP连接总数超过15000时，设备将拒绝所有安全域间的新的TCP连接请求，并会产生流量告警，输出到信息中心。流量恢复到下限阈值12000以下时，允许建立新的TCP连接，并产生流量恢复日志，输出到信息中心。

缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值为16384，下限阈值为12288。

----结束

6.13.2 配置基于安全区域的流量统计和监控功能

背景信息

基于安全区域的流量统计和监控，对本安全区域和其他安全区域之间的数据流生效，即单板会统计本安全区域和其他所有安全域间建立的TCP、UDP等连接总数。当本安全区域和其他所有安全域间建立的连接总数或者某个方向的连接总数超过配置的阈值时，单板采取限制连接数措施，直至连接数降至阈值以下。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall zone zone-name**，进入安全区域视图。

步骤3 执行命令**statistics zone enable { inzone | outzone }**，使能安全区域流量统计和监控。

缺省情况下，设备未使能对安全区域的流量统计和监控功能。

步骤4 （可选）执行命令**statistics connect-number zone { inzone | outzone } { icmp | tcp | udp } high high-threshold low low-threshold**，配置安全区域流量统计和监控的阈值。

安全区域的流量统计功能可以针对ICMP/TCP/UDP连接，在入和出两个方向配置其阈值。例如当出方向TCP连接数阈值上限为15000，下限为13000时，当本区域向其他区

域发起的TCP连接总数超过15000，设备将拒绝本区域向其他区域发起新的TCP连接请求，当本区域向其他区域发起的TCP连接总数下降到13000时，才允许本区域向其他区域发起新的TCP连接请求。

缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值为16384，下限阈值为12288。

----结束

6.13.3 配置基于 IP 的流量统计和监控

背景信息

基于IP地址的流量统计和监控，用于统计和监控安全区域中单个IP地址所建立的TCP/UDP连接。设备通过分析源IP地址发起或目的地址接收的TCP或UDP连接总数是否超过设定的阈值，可以确定是否需要限制该方向的新的连接的发起，以防止系统受到恶意的攻击或因系统太忙而发生拒绝服务的情况。

当TCP/UDP连接数降至阈值以下后，源IP地址或目的地址可以重新发起或者接受TCP或UDP连接。

基于IP地址的流量统计和监控支持对某个源IP地址和某个地址段IP地址进行流量统计和监控。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall zone zone-name**，创建一个安全区域或者进入一个已存在的安全区域视图。

步骤3 执行命令**statistics ip enable { inzone | outzone }**，使能IP流量统计和监控。

缺省情况下，设备未使能对安全区域的IP流量统计和监控功能。

步骤4 （可选）执行命令**statistics connect-number ip [range beginip endip] { inzone | outzone } { icmp | tcp | udp } high high-threshold low low-threshold**，配置安全区域IP流量统计和监控的阈值。

IP流量统计功能可以针对ICMP/TCP/UDP连接，在入和出两个方向配置其阈值。例如当入方向TCP连接数阈值上限为10000，下限为8000时，当本区域向其他区域发起的TCP连接总数超过10000，设备将拒绝本区域向其他区域发起新的TCP连接请求，当本区域向其他区域发起的TCP连接总数下降到8000时，才允许本区域向其他区域发起新的TCP连接请求。

缺省情况下，防火墙安全区域对各协议报文的连接数的上限阈值为16384，下限阈值为12288。

----结束

6.13.4 检查流量统计和监控的配置结果

操作步骤

- 执行命令**display firewall statistics system**，查看系统流量统计和监控的相关信息。

- 执行命令**display firewall statistics zone zone-name { inzone | outzone } all**，查看安全区域流量统计和监控的相关信息。
- 执行命令**display firewall statistics zone-ip zone-name**，查看安全区域IP流量统计和监控的相关信息。

----结束

6.14 配置防火墙日志

背景信息

流日志实时向日志主机输出，因此首先需要配置日志主机。包括日志主机的IP地址、端口号，以及设备和日志主机通讯所使用的源IP地址和源端口号。

在安全域间可以根据ACL来设置记录流日志的条件，同时可以针对出方向和入方向分别配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall log binary-log host host-ip-address host-port source source-ip-address source-port [vpn-instance vpn-instance-name]**，配置流日志主机。

缺省情况下，流日志主机未配置。

步骤3 执行命令**firewall log { all | blacklist | defend | session | statistics | packet-filter } enable**，使能防火墙日志功能。

缺省情况下，防火墙日志功能未使能。

说明

为了提高配置效率，可以执行命令**firewall log all enable**使能防火墙日志功能。此后，防火墙的流量统计日志、攻击日志和黑名单日志功能生效，包过滤日志还需要**配置安全域间的防火墙包过滤日志功能**，流日志还需要**配置安全域间的防火墙流日志功能**才会生效。

- 配置安全域间的防火墙包过滤日志功能
 - a. 执行命令**firewall interzone zone-name1 zone-name2**，进入安全域间视图。
 - b. 执行命令**packet-filter logging [{ inbound | outbound } [permit | deny]]**，使能安全域间的包过滤日志功能。
缺省情况下，安全域间的包过滤日志功能处于未使能状态。
 - c. 执行命令**quit**，进入系统视图。
- 配置安全域间的防火墙流日志功能
 - a. 执行命令**firewall interzone zone-name1 zone-name2**，进入安全域间视图。
 - b. 执行命令**session-log acl-number { inbound | outbound }**，配置记录流日志的条件。
缺省情况下，安全域间没有配置记录流日志的条件。
 - c. 执行命令**quit**，进入系统视图。

步骤4 （可选）执行命令**firewall log { blacklist | defend | session | statistics | packet-filter } log-interval time**，配置日志输出时间间隔。

缺省情况下，设备定时输出日志的时间间隔为30秒。

----结束

检查配置结果

- 执行**display firewall log configuration**命令，查看防火墙日志的相关信息。

6.15 配置虚拟防火墙

6.15.1 配置 VPN 实例划分虚拟防火墙

背景信息

虚拟防火墙通过配置VPN实例实现，一个VPN实例对应一个虚拟防火墙，因此在配置虚拟防火墙功能时，需要先创建VPN实例，再将接口绑定VPN实例。具有相同VPN实例的接口，位于同一个虚拟防火墙，可独立部署安全策略。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**ip vpn-instance vpn-instance-name**，创建VPN实例，并进入VPN实例视图。

步骤3 （可选）执行命令**description description-information**，记录VPN实例的描述信息。

步骤4 执行命令**route-distinguisher route-distinguisher**，配置VPN实例的路由标识。

创建VPN实例后，需要为该VPN实例指定路由标识，否则不能进行后续配置。

步骤5 执行命令**interface interface-type interface-number**，进入接口视图。

步骤6 执行命令**ip binding vpn-instance vpn-instance-name**，配置接口绑定VPN实例。

配置接口时，需要首先配置接口绑定VPN实例，再配置接口IP地址。如果顺序相反，则最初配置的接口IP地址被删除，需要重新配置。

步骤7 执行命令**ip address ip-address { mask | mask-length }**配置接口的IP地址。

----结束

6.15.2 配置虚拟防火墙的安全特性

背景信息

配置虚拟防火墙的安全功能，和正常配置防火墙安全功能的步骤相同，每个虚拟防火墙需要独立配置，以满足不同的防火墙业务需求，用户可以选择配置如下功能：

- 配置包过滤防火墙
- 配置ASPF

- 配置端口映射
- 配置防火墙会话表老化时间
- 配置攻击防范

配置虚拟防火墙的如下功能时，用户需要指定VPN实例，根据指定的VPN实例，仅对相应的虚拟防火墙生效。

- [配置手工添加黑名单](#)
- [配置手工添加白名单](#)
- [配置ICMP flood攻击防范](#)
- [配置SYN flood攻击防范](#)
- [配置UDP flood攻击防范](#)

操作步骤

- 配置虚拟防火墙黑名单
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**firewall blacklist enable**，使能黑名单功能。
 - c. 执行命令**firewall blacklist ip-address [vpn-instance vpn-instance-name] [expire-time minutes]**，添加黑名单表项。
- 配置虚拟防火墙白名单
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**firewall whitelist ip-address [vpn-instance vpn-instance-name] [expire-time minutes]**，添加白名单表项。
- 配置ICMP flood攻击防范
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**firewall defend icmp-flood enable**，使能ICMP Flood攻击防范功能。
 - c. 执行命令**firewall defend icmp-flood { ip ip-address [vpn-instance vpn-instance-name] | zone zone-name } [max-rate rate-value]**，配置ICMP Flood攻击防范参数。
- 配置SYN flood攻击防范
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**firewall defend syn-flood enable**，使能SYN Flood攻击防范。
 - c. 执行命令**firewall defend syn-flood { ip ip-address [vpn-instance vpn-instance-name] | zone zone-name } [max-rate rate-value] [tcp-proxy { auto | off | on }]**，配置SYN Flood攻击防范参数。
- 配置UDP flood攻击防范
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**firewall defend udp-flood enable**，使能UDP Flood攻击防范。
 - c. 执行命令**firewall defend udp-flood { ip ip-address [vpn-instance vpn-instance-name] | zone zone-name } [max-rate rate-value]**，配置UDP Flood攻击防范参数。

----结束

6.15.3 检查虚拟防火墙的配置结果

操作步骤

- 执行**display firewall zone** [*zone-name*] [**interface** | **priority**]命令，查看安全域的相关信息。
- 执行**display firewall interzone** [*zone-name1 zone-name2*]命令，查看安全域间的相关信息。
- 执行**display firewall blacklist** { **all** | *ip-address* [**vpn-instance** *vpn-instance-name*] | **dynamic** | **static** | **vpn-instance** *vpn-instance-name* }命令，查看黑名单的相关信息。
- 执行**display firewall whitelist** { **all** | *ip-address* [**vpn-instance** *vpn-instance-name*] | **vpn-instance** *vpn-instance-name* }命令，查看白名单的相关信息。
- 执行**display firewall defend** { **flag** { **icmp-flood** | **syn-flood** | **udp-flood** } [**ip** [*ip-address* [**vpn-instance** *vpn-instance-name*]] | **zone** [*zone-name*]] | *other-attack-type* }命令，查看攻击防范的相关信息。

----结束

6.16 配置防火墙主备

6.16.1 配置 HSB 主备服务

背景信息

HSB主备服务负责在两个互为备份的设备间建立主备备份通道，维护主备通道的链路状态，为其他业务提供报文的收发服务，并在备份链路发生故障时通知主备业务备份组进行相应的处理。

HSB主备服务主要包括两个方面：

- 建立主备备份通道：通过配置主备服务本端和对端的IP地址和端口号，从而建立主备机制报文发送的TCP通道，为其他业务提供报文的收发以及链路状态变化通知服务。
- 维护主备通道的链路状态：通过发送主备服务报文和重传等机制来防止TCP较长时间中断但协议栈没有检测到该连接中断。如果在主备服务报文时间间隔与重传次数乘积的时间内还未收到对端发送的主备服务报文，设备则会收到异常通知，并且准备重建主备备份通道。

说明

- HSB主备备份通道参数必须在本端和对端同时配置。本端的源IP地址、目的IP地址、源端口和目的端口分别为对端的目的IP地址、源IP地址、目的端口和源端口。
- 主备服务报文的相关参数，包括发送时间间隔、重传次数在主备两端必须配置一致。
- 配置共享密钥时需要注意：
 - 配置共享密钥会影响双机热备的性能，在网络环境安全的情况下，不建议配置该功能。如果需要配置，请确保主备两端的共享密钥必须配置一致，否则会导致HSB连接不稳定，反复连接断开。
 - 命令**key**必须先于命令**service-ip-port**配置，否则会导致命令**key**配置失败。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**hsb-service service-index**，创建HSB主备服务并进入HSB主备服务视图。
缺省情况下，未创建HSB主备服务。
- 步骤3** （可选）执行命令**key cipher key-string**，配置HSB主备两端的共享密钥。
缺省情况下，未配置HSB主备两端的共享密钥。
- 步骤4** 执行命令**service-ip-port local-ip local-ip-address peer-ip peer-ip-address local-data-port local-port peer-data-port peer-port**，配置建立HSB主备备份通道的IP地址和端口号。
缺省情况下，未配置HSB主备备份通道的IP地址和端口号。
- 步骤5** （可选）执行命令**service-keep-alive detect retransmit retransmit-times interval interval-value**，配置HSB主备服务报文的重传次数和发送间隔。
缺省情况下，报文的重传次数为5，发送间隔为3秒。
- 结束

6.16.2 配置 HSB 备份组

背景信息

HSB备份组负责通知各个业务模块进行批量备份、实时备份和状态同步。各个业务备份功能依赖于业务备份组提供的状态协商和事件通知机制，实现业务信息的主备同步。

HSB主备业务备份组依赖于HSB主备服务处理提供的主备通道，进行备份信息的同步，并响应主备服务处理的链路通断事件。需要为HSB备份组绑定HSB主备服务，才能使HSB备份组正常工作。此外，HSB备份组还需要通过与VRRP备份组绑定，根据VRRP的状态协商出业务的主备状态；并通过监控所绑定的主备通道状态和VRRP状态的变化，通知各个业务模块进行批量备份、实时备份和状态同步。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**hsb-group group-index**，创建HSB备份组并进入HSB备份组视图。
缺省情况下，设备上未创建HSB备份组。
- 步骤3** 执行命令**bind-service service-index**，配置HSB备份组绑定的HSB主备服务。
缺省情况下，HSB备份组未绑定HSB主备服务。
- 步骤4** 执行命令**track vrrp vrid virtual-router-id interface interface-type interface-number**，配置HSB备份组绑定的VRRP备份组。
缺省情况下，HSB备份组未绑定VRRP备份组。
- 步骤5** 执行命令**quit**，进入系统视图。

步骤6 （可选）执行命令**hsb-service-type firewall hsb-group *group-index***，配置防火墙业务绑定HSB备份组。

 说明

主备通道上不能配置STP、VRRP、MTU等业务。

HSB备份组使能后不能进行防火墙业务与HSB备份组绑定的操作，请在使能HSB备份组前进行防火墙业务的绑定。

----结束

6.16.3 使能 HSB 备份组

背景信息

HSB备份组使能后，对HSB备份组的相关配置才会生效，HSB备份组才会在状态发生变化时通知相应的业务模块进行处理。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**hsb-group *group-index***，进入HSB备份组视图。

步骤3 执行命令**hsb enable**，使能HSB备份组。

----结束

6.16.4 检查 VRRP 热备份配置结果

操作步骤

- 执行命令**display hsb-group *group-index***，查看HSB备份组的信息。
- 执行命令**display hsb-service *service-index***，命令查看HSB主备服务的信息。

----结束

6.17 维护防火墙

6.17.1 查看防火墙配置

操作步骤

- 执行命令**display firewall zone [*zone-name*] [*interface* | *priority*]**，查看全部或指定安全区域的配置信息。
- 执行命令**display firewall interzone [*zone-name1* *zone-name2*]**，查看安全域间的信息。
- 执行命令**display firewall blacklist configuration**，查看防火墙黑名单功能是否使能。

- 执行命令**display firewall blacklist** { all | ip-address [vpn-instance vpn-instance-name] | dynamic | static | vpn-instance vpn-instance-name }, 查看防火墙黑名单表项的内容。
- 执行命令**display firewall whitelist** { all | ip-address [vpn-instance vpn-instance-name] | vpn-instance vpn-instance-name }, 查看防火墙白名单表项的信息。
- 执行命令**display firewall statistics system** [normal all | defend], 查看防火墙的系统流量统计信息。
- 执行命令**display firewall statistics zone** zone-name { inzone | outzone } all, 查看安全区域的流量统计和监控信息。
- 执行命令**display firewall statistics zone-ip** zone-name, 查看指定域下域的流量监控使能情况与各种协议配置的监控阈值。
- 执行命令**display firewall-nat session aging-time**, 查看防火墙设备上会话表项的超时时间。
- 执行命令**display port-mapping** [dns | ftp | http | rtsp | sip | port port-number | pptp], 查看指定的应用层协议和端口的映射关系。
- 执行命令**display firewall defend** { flag | { icmp-flood | syn-flood | udp-flood } [ip [ip-address [vpn-instance vpn-instance-name]] | zone [zone-name]] | other-attack-type }, 查看各种攻击防范功能的使能状态和配置信息。
- 执行命令**display firewall log configuration**, 查看防火墙日志的全局配置信息。
- 执行命令**display firewall session** { all [verbose] | number }或**display firewall session protocol** { protocol-number | protocol-name } [source source-address [source-port]] [destination destination-address [destination-port]] [verbose]或**display firewall session destination** destination-address [destination-port] [verbose]或**display firewall session source** source-address [source-port] [destination destination-address [destination-port]] [verbose], 查看Firewall的流表信息。
- 执行命令**display firewall ipv6 session** { all [verbose] | number }或**display firewall ipv6 session protocol** { protocol-number | protocol-name } [source source-address [source-port]] [destination destination-address [destination-port]] [verbose]或**display firewall ipv6 session destination** destination-address [destination-port] [verbose]或**display firewall ipv6 session source** source-address [source-port] [destination destination-address [destination-port]] [verbose], 查看IPv6的Firewall的流表信息。
- 执行命令**display firewall app** { servermap | session } table statistics, 查看防火墙应用层表项的统计信息。
- 执行命令**display firewall app session table** [application-protocol { dns | ftp | http | pptp | rtsp | sip }] [source-ip ip-address [port-number]] [destination-ip ip-address [port-number]], 查看应用层流表信息。
- 执行命令**display session** { all [verbose] | number }或**display session destination** destination-address [destination-port] [verbose]或**display session source** source-address [source-port] [destination destination-address [destination-port]] [verbose]或**display session protocol** { protocol-number | protocol-name } [source source-address [source-port]] [destination destination-address [destination-port]] [verbose], 查看流表信息。

----结束

6.17.2 清除防火墙统计信息

背景信息

为了能够清楚地查看某一时间段内设备正常通信的报文，可以执行下面的命令先清空之前的报文统计数。

操作步骤

- 在系统视图下，执行命令**clear firewall statistics system normal**，清空系统正常报文的报文统计数。
- 在系统视图下，执行命令**clear firewall statistics zone zone-name**，清空安全区域正常报文的报文统计数。

----结束

6.17.3 清除防火墙应用层表项的统计信息

背景信息

在需要重新统计防火墙应用层表项的统计信息时执行本任务。清除统计信息成功后，防火墙应用层表项的统计信息将被清零。

说明

清除防火墙应用层表项统计信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

- 执行命令**reset firewall app { servermap | session } table statistics**，清除防火墙应用层表项的统计信息。

----结束

6.17.4 清除防火墙攻击防范的统计信息

背景信息

在需要重新统计防火墙攻击防范的信息时，可以使用本命令清除已统计的防火墙攻击防范信息。清除统计信息成功后，防火墙攻击防范信息将被清零。

说明

清除防火墙攻击防范信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

- 执行命令**reset firewall statistics system defend**，清除防火墙攻击防范的统计信息。

----结束

6.18 防火墙配置举例

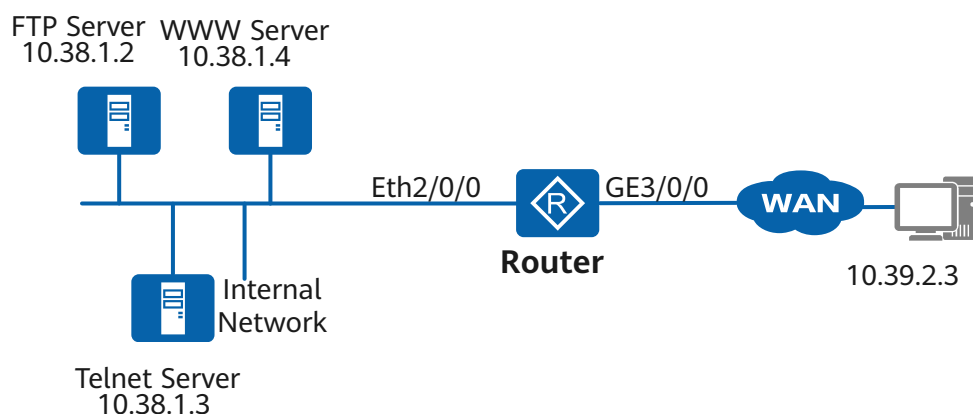
6.18.1 配置 ACL 包过滤防火墙典型示例

组网需求

如图6-22所示，Router的接口Eth2/0/0连接一个高安全优先级的内部网络，接口GE3/0/0连接低安全优先级的外部网络，需要对内部网络和外部网络之间的通信实施包过滤。具体要求如下：

- 外部特定主机（10.39.2.3）允许访问内部网络中的服务器。
- 其余的访问均不允许。

图 6-22 配置 ACL 包过滤组网图



配置思路

采用如下思路配置ACL包过滤防火墙：

1. 配置安全区域和安全域间。
2. 将接口加入安全区域。
3. 配置ACL。
4. 在安全域间配置基于ACL的包过滤。

操作步骤

步骤1 在Router上配置安全区域和安全域间。

```
<Huawei> system-view
[Huawei] firewall zone trust
[Huawei-zone-trust] priority 14
[Huawei-zone-trust] quit
[Huawei] firewall zone untrust
[Huawei-zone-untrust] priority 1
[Huawei-zone-untrust] quit
[Huawei] firewall interzone trust untrust
```

```
[Huawei-interzone-trust-untrust] firewall enable
[Huawei-interzone-trust-untrust] quit
```

步骤2 在Router上将接口加入安全区域。

```
[Huawei] vlan 100
[Huawei-vlan100] quit
[Huawei] interface vlanif 100
[Huawei-Vlanif100] ip address 10.38.1.1 24
[Huawei-Vlanif100] quit
[Huawei] interface ethernet 2/0/0
[Huawei-Ethernet2/0/0] port link-type access
[Huawei-Ethernet2/0/0] port default vlan 100
[Huawei-Ethernet2/0/0] quit
[Huawei] interface vlanif 100
[Huawei-Vlanif100] zone trust
[Huawei-Vlanif100] quit
[Huawei] interface gigabitethernet 3/0/0
[Huawei-GigabitEthernet3/0/0] ip address 10.39.2.1 24
[Huawei-GigabitEthernet3/0/0] zone untrust
[Huawei-GigabitEthernet3/0/0] quit
```

步骤3 在Router上配置ACL。

```
[Huawei] acl 3102
[Huawei-acl-adv-3102] rule permit tcp source 10.39.2.3 0.0.0.0 destination 10.38.1.2 0.0.0.0
[Huawei-acl-adv-3102] rule permit tcp source 10.39.2.3 0.0.0.0 destination 10.38.1.3 0.0.0.0
[Huawei-acl-adv-3102] rule permit tcp source 10.39.2.3 0.0.0.0 destination 10.38.1.4 0.0.0.0
[Huawei-acl-adv-3102] rule deny ip
[Huawei-acl-adv-3102] quit
```

步骤4 在Router上配置包过滤。

```
[Huawei] firewall interzone trust untrust
[Huawei-interzone-trust-untrust] packet-filter 3102 inbound
[Huawei-interzone-trust-untrust] quit
```

步骤5 验证配置结果。

配置成功后，仅特定主机（10.39.2.3）可以访问内部服务器。

在Router上执行**display firewall interzone [zone-name1 zone-name2]**命令，结果如下。

```
[Huawei] display firewall interzone trust untrust
interzone trust untrust
firewall enable
packet-filter default deny inbound
packet-filter default permit outbound
packet-filter 3102 inbound
```

----结束

配置文件

Router的配置文件

```
#
vlan batch 100
#
acl number 3102
rule 5 permit tcp source 10.39.2.3 0 destination 10.38.1.2 0
rule 10 permit tcp source 10.39.2.3 0 destination 10.38.1.3 0
rule 15 permit tcp source 10.39.2.3 0 destination 10.38.1.4 0
rule 20 deny ip
#
interface Vlanif100
ip address 10.38.1.1 255.255.255.0
zone trust
#
```

```
firewall zone trust
priority 14
#
firewall zone untrust
priority 1
#
firewall interzone trust untrust
firewall enable
packet-filter 3102 inbound
#
interface Ethernet2/0/0
port link-type access
port default vlan 100
#
interface GigabitEthernet3/0/0
ip address 10.39.2.1 255.255.255.0
zone untrust
#
return
```

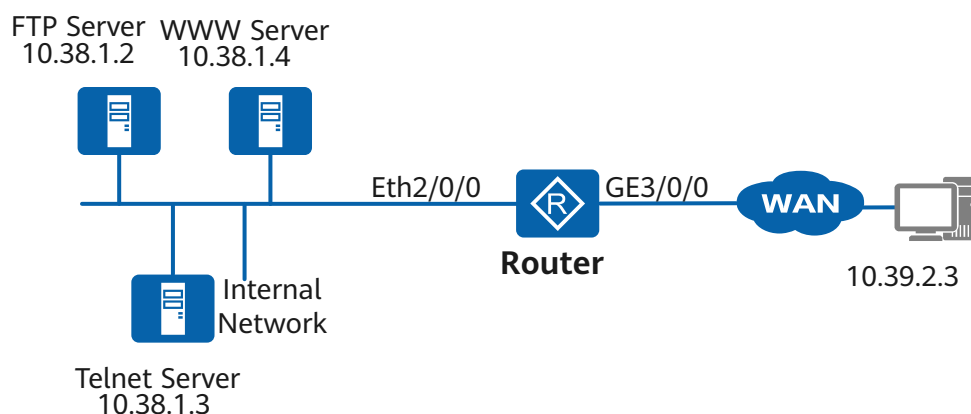
6.18.2 配置 ASPF 和端口映射示例

组网需求

如图6-23所示，Router的接口Eth2/0/0连接一个高安全优先级的内部网络，接口GE3/0/0连接低安全优先级的外部网络，需要对内部网络和外部网络之间的通信实施包过滤和ASPF检查。具体要求如下：

- 外部特定主机（10.39.2.3）允许访问内部网络中的服务器。
- 其余的访问均不允许。
- 对上述访问的连接进行FTP状态检查，过滤不符合状态的报文。
- 对于外部主机访问FTP服务器的报文，识别2121端口为FTP协议。

图 6-23 配置 ASPF 和端口映射组网图



配置思路

采用如下思路配置ASPF和端口映射：

1. 配置安全区域和安全域间。
2. 将接口加入安全区域。

3. 配置ACL。
4. 在安全域间配置基于ACL的包过滤。
5. 在安全域间配置ASPF。
6. 配置端口映射，将2121端口映射为FTP协议通信端口。

操作步骤

步骤1 在Router上配置安全区域和安全域间。

```
<Huawei> system-view
[Huawei] firewall zone trust
[Huawei-zone-trust] priority 14
[Huawei-zone-trust] quit
[Huawei] firewall zone untrust
[Huawei-zone-untrust] priority 1
[Huawei-zone-untrust] quit
[Huawei] firewall interzone trust untrust
[Huawei-interzone-trust-untrust] firewall enable
[Huawei-interzone-trust-untrust] quit
```

步骤2 在Router上将接口加入安全区域。

```
[Huawei] vlan 100
[Huawei-vlan100] quit
[Huawei] interface vlanif 100
[Huawei-Vlanif100] ip address 10.38.1.1 24
[Huawei-Vlanif100] quit
[Huawei] interface ethernet 2/0/0
[Huawei-Ethernet2/0/0] port link-type access
[Huawei-Ethernet2/0/0] port default vlan 100
[Huawei-Ethernet2/0/0] quit
[Huawei] interface vlanif 100
[Huawei-Vlanif100] zone trust
[Huawei-Vlanif100] quit
[Huawei] interface gigabitethernet 3/0/0
[Huawei-GigabitEthernet3/0/0] ip address 10.39.2.1 24
[Huawei-GigabitEthernet3/0/0] zone untrust
[Huawei-GigabitEthernet3/0/0] quit
```

步骤3 在Router上配置ACL。

```
[Huawei] acl 2102
[Huawei-acl-basic-2102] rule permit source 10.38.1.2 0.0.0.0
[Huawei-acl-basic-2102] quit
[Huawei] acl 3102
[Huawei-acl-adv-3102] rule permit tcp source 10.39.2.3 0.0.0.0 destination 10.38.1.2 0.0.0.0
[Huawei-acl-adv-3102] rule permit tcp source 10.39.2.3 0.0.0.0 destination 10.38.1.3 0.0.0.0
[Huawei-acl-adv-3102] rule permit tcp source 10.39.2.3 0.0.0.0 destination 10.38.1.4 0.0.0.0
[Huawei-acl-adv-3102] rule deny ip
[Huawei-acl-adv-3102] quit
```

步骤4 在Router上配置包过滤。

```
[Huawei] firewall interzone trust untrust
[Huawei-interzone-trust-untrust] packet-filter 3102 inbound
```

步骤5 在Router上配置ASPF。

```
[Huawei-interzone-trust-untrust] detect aspf ftp
[Huawei-interzone-trust-untrust] quit
```

步骤6 在Router上配置端口映射。

```
[Huawei] port-mapping ftp port 2121 acl 2102
```

步骤7 验证配置结果。

在Router上执行**display firewall interzone zone-name1 zone-name2**，结果如下。

```
[Huawei] display firewall interzone trust untrust
interzone trust untrust
firewall enable
packet-filter default deny inbound
packet-filter default permit outbound
packet-filter 3102 inbound
detect aspf ftp
```

在Router上执行**display port-mapping ftp**，结果如下。

```
[Huawei] display port-mapping ftp
-----
Service  Port    Acl    Type
-----
ftp      21      system defined
ftp      2121    2102   user  defined
-----
Total number is : 2
```

----结束

配置文件

Router的配置文件

```
#
vlan batch 100
#
acl number 2102
rule 5 permit source 10.38.1.2 0
#
acl number 3102
rule 5 permit tcp source 10.39.2.3 0 destination 10.38.1.2 0
rule 10 permit tcp source 10.39.2.3 0 destination 10.38.1.3 0
rule 15 permit tcp source 10.39.2.3 0 destination 10.38.1.4 0
rule 20 deny ip
#
port-mapping ftp port 2121 acl 2102
#
interface Vlanif100
ip address 10.38.1.1 255.255.255.0
zone trust
#
firewall zone trust
priority 14
#
firewall zone untrust
priority 1
#
firewall interzone trust untrust
firewall enable
packet-filter 3102 inbound
detect aspf ftp
#
interface Ethernet2/0/0
port link-type access
port default vlan 100
#
interface GigabitEthernet3/0/0
ip address 10.39.2.1 255.255.255.0
zone untrust
#
return
```

6.18.3 配置黑名单示例

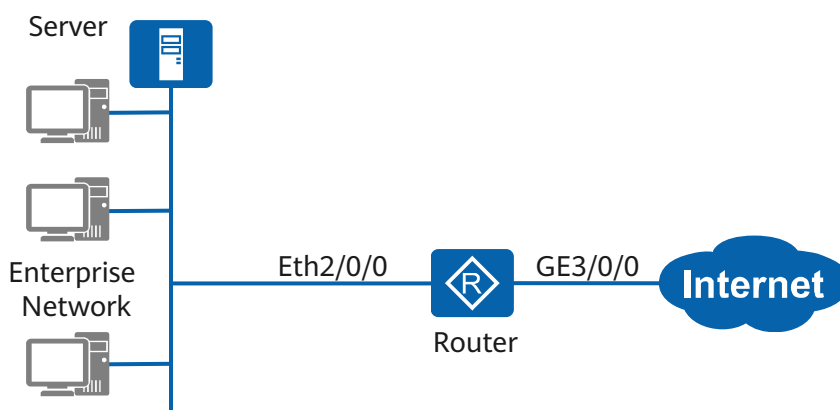
组网需求

如图6-24所示，Router的接口Eth2/0/0连接一个高安全优先级的内部网络，接口GE3/0/0连接低安全优先级的外部网络。

需要对互联网访问企业网的流量配置地址扫描攻击防范和黑名单功能，一旦发现某个IP地址对企业网发起了地址扫描攻击，则自动把该IP地址加入黑名单。其中最大连接速率为5000pps，黑名单超时时间为30分钟。

另外，由于发现IP地址1.1.1.2多次企图对企业网发起攻击，因此将其手工加入黑名单，永久有效。

图 6-24 配置黑名单组网图



配置思路

采用如下思路配置黑名单：

1. 配置安全区域和安全域间。
2. 将接口加入安全区域。
3. 使能防火墙黑名单功能。
4. 添加黑名单表项。
5. 使能地址扫描或端口扫描攻击功能。
6. 配置地址扫描或端口扫描攻击的max-rate及动态黑名单老化时间。

操作步骤

步骤1 在Router上配置安全区域和安全域间。

```
[Huawei] firewall zone trust
[Huawei-zone-trust] priority 14
[Huawei-zone-trust] quit
[Huawei] firewall zone untrust
[Huawei-zone-untrust] priority 1
[Huawei-zone-untrust] quit
[Huawei] firewall interzone trust untrust
[Huawei-interzone-trust-untrust] firewall enable
[Huawei-interzone-trust-untrust] quit
```


步骤2 在Router上将接口加入安全区域。

```
[Huawei] vlan 100
[Huawei-vlan100] quit
[Huawei] interface vlanif 100
[Huawei-Vlanif100] ip address 10.38.1.1 24
[Huawei-Vlanif100] quit
[Huawei] interface ethernet 2/0/0
[Huawei-Ethernet2/0/0] port link-type access
[Huawei-Ethernet2/0/0] port default vlan 100
[Huawei-Ethernet2/0/0] quit
[Huawei] interface vlanif 100
[Huawei-Vlanif100] zone trust
[Huawei-Vlanif100] quit
[Huawei] interface gigabitethernet 3/0/0
[Huawei-GigabitEthernet3/0/0] ip address 1.1.2.1 24
[Huawei-GigabitEthernet3/0/0] zone untrust
[Huawei-GigabitEthernet3/0/0] quit
```

步骤3 使能黑名单功能。

```
[Huawei] firewall blacklist enable
```

步骤4 添加黑名单表项。

```
[Huawei] firewall blacklist 1.1.1.2
```

步骤5 使能IP地址和端口扫描攻击防范。

```
[Huawei] firewall defend ip-sweep enable
[Huawei] firewall defend port-scan enable
```

步骤6 配置地址扫描或端口扫描攻击的max-rate及动态黑名单老化时间。

```
[Huawei] firewall defend ip-sweep max-rate 5000
[Huawei] firewall defend ip-sweep blacklist-expire-time 30
[Huawei] firewall defend port-scan max-rate 5000
[Huawei] firewall defend port-scan blacklist-expire-time 30
```

步骤7 验证配置结果。

在Router上执行**display firewall interzone [zone-name1 zone-name2]**命令，结果如下。

```
[Huawei] display firewall interzone trust untrust
interzone trust untrust
firewall enable
packet-filter default deny inbound
packet-filter default permit outbound
```

在Router上执行**display firewall blacklist all**命令，结果如下。

```
[Huawei] display firewall blacklist all
Firewall Blacklist Items :
-----
IP-Address    Reason      Expire-Time(m)  VPN-Instance
-----
1.1.1.2       Manual      Permanent
-----
total number is : 1
```

在Router上执行**display firewall defend**查看地址扫描和端口扫描的配置结果，如下。

```
[Huawei] display firewall defend port-scan
defend-flag      : enable
max-rate         : 5000 (pps)
blacklist-expire-time : 30 (m)

[Huawei] display firewall defend ip-sweep
defend-flag      : enable
max-rate         : 5000 (pps)
```

```
blacklist-expire-time : 30 (m)
```

----结束

配置文件

Router的配置文件

```
#
firewall defend ip-sweep enable
firewall defend port-scan enable
firewall defend ip-sweep max-rate 5000
firewall defend ip-sweep blacklist-expire-time 30
firewall defend port-scan max-rate 5000
firewall defend port-scan blacklist-expire-time 30
#
firewall blacklist enable
firewall blacklist 1.1.1.2
#
vlan batch 100
#
interface Vlanif100
ip address 10.38.1.1 255.255.255.0
zone trust
#
firewall zone trust
priority 14
#
firewall zone untrust
priority 1
#
firewall interzone trust untrust
firewall enable
#
interface Ethernet2/0/0
port link-type access
port default vlan 100
#
interface GigabitEthernet3/0/0
ip address 1.1.2.1 255.255.255.0
zone untrust
#
return
```

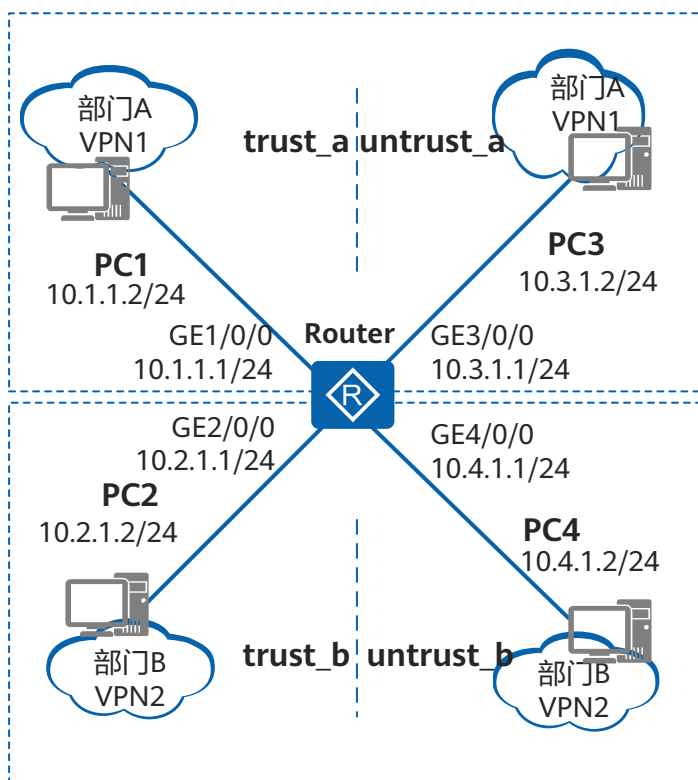
6.18.4 配置虚拟防火墙黑名单示例

组网需求

在Router上，每个VPN实例均可以独立部署防火墙，互不影响，即虚拟防火墙。

如图6-25所示，部门A和部门B通过在Router上部署VPN实例划分虚拟防火墙，实现部门间隔离。防火墙策略独立部署，分别为每个VPN网络划分安全区域。其中部门A发现VPN1网络上存在攻击者，源IP为10.3.1.2，需要为VPN1配置黑名单。如果收到报文的源地址为攻击者的IP地址，则丢弃该报文。

图 6-25 配置虚拟防火墙黑名单组网图



配置思路

配置虚拟防火墙黑名单的思路如下：

1. 在Router上配置VPN，通过VPN实例，实现部门A和部门B的隔离。
2. 在Router上划分不同的安全区域。
3. 在Router上为VPN1配置黑名单，丢弃攻击者的报文。

操作步骤

步骤1 在Router上配置VPN

分别为部门A和部门B配置VPN实例vpn1和vpn2。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] ip vpn-instance vpn1
[Router-vpn-instance-vpn1] ipv4-family
[Router-vpn-instance-vpn1-af-ipv4] route-distinguisher 100:1
[Router-vpn-instance-vpn1-af-ipv4] quit
[Router-vpn-instance-vpn1] quit
[Router] ip vpn-instance vpn2
[Router-vpn-instance-vpn2] ipv4-family
[Router-vpn-instance-vpn2-af-ipv4] route-distinguisher 200:1
[Router-vpn-instance-vpn2-af-ipv4] quit
[Router-vpn-instance-vpn2] quit
```

为私网接口绑定VPN实例，配置私网IP地址作为网关地址。

```
[Router] interface gigabitethernet 1/0/0
[Router-GigabitEthernet1/0/0] ip binding vpn-instance vpn1
[Router-GigabitEthernet1/0/0] ip address 10.1.1.1 255.255.255.0
[Router-GigabitEthernet1/0/0] quit
[Router] interface gigabitethernet 2/0/0
[Router-GigabitEthernet2/0/0] ip binding vpn-instance vpn2
[Router-GigabitEthernet2/0/0] ip address 10.2.1.1 255.255.255.0
[Router-GigabitEthernet2/0/0] quit
[Router] interface gigabitethernet 3/0/0
[Router-GigabitEthernet3/0/0] ip binding vpn-instance vpn1
[Router-GigabitEthernet3/0/0] ip address 10.3.1.1 255.255.255.0
[Router-GigabitEthernet3/0/0] quit
[Router] interface gigabitethernet 4/0/0
[Router-GigabitEthernet4/0/0] ip binding vpn-instance vpn2
[Router-GigabitEthernet4/0/0] ip address 10.4.1.1 255.255.255.0
[Router-GigabitEthernet4/0/0] quit
```

步骤2 在Router上划分安全区域

在Router上配置VPN1的安全区域和安全域间。

```
[Router] firewall zone trust_a
[Router-zone-trust_a] priority 15
[Router-zone-trust_a] quit
[Router] firewall zone untrust_a
[Router-zone-untrust_a] priority 1
[Router-zone-untrust_a] quit
[Router] firewall interzone trust_a untrust_a
[Router-interzone-trust_a-untrust_a] firewall enable
[Router-interzone-trust_a-untrust_a] quit
```

在Router上配置VPN2的安全区域和安全域间。

```
[Router] firewall zone trust_b
[Router-zone-trust_b] priority 30
[Router-zone-trust_b] quit
[Router] firewall zone untrust_b
[Router-zone-untrust_b] priority 5
[Router-zone-untrust_b] quit
[Router] firewall interzone trust_b untrust_b
[Router-interzone-trust_b-untrust_b] firewall enable
[Router-interzone-trust_b-untrust_b] quit
```

在Router上将接口加入安全区域。

```
[Router] interface gigabitethernet 1/0/0
[Router-GigabitEthernet1/0/0] zone trust_a
[Router-GigabitEthernet1/0/0] quit
[Router] interface gigabitethernet 2/0/0
[Router-GigabitEthernet2/0/0] zone trust_b
[Router-GigabitEthernet2/0/0] quit
[Router] interface gigabitethernet 3/0/0
[Router-GigabitEthernet3/0/0] zone untrust_a
[Router-GigabitEthernet3/0/0] quit
[Router] interface gigabitethernet 4/0/0
[Router-GigabitEthernet4/0/0] zone untrust_b
[Router-GigabitEthernet4/0/0] quit
```

步骤3 在Router上为VPN1配置黑名单

全局使能黑名单功能。

```
[Router] firewall blacklist enable
```

为VPN1添加黑名单表项。

```
[Router] firewall blacklist 10.3.1.2 vpn-instance vpn1
```

步骤4 验证配置结果

配置成功后，在Router上执行**display firewall interzone**命令可查看安全域间的策略。

```
[Router] display firewall interzone
interzone trust_a untrust_a
firewall enable
packet-filter default deny inbound
packet-filter default permit outbound

interzone trust_b untrust_b
firewall enable
packet-filter default deny inbound
packet-filter default permit outbound

total number is : 2
```

在Router上执行**display firewall blacklist all**命令可查看黑名单信息。

```
[Router] display firewall blacklist all
Firewall blacklist items :
-----
IP-Address      Reason      Expire-Time(m) VPN-Instance
-----
10.3.1.2        Manual      Permanent    vpn1
-----
Total number is : 1
```

PC3的报文无法通过虚拟防火墙VPN1。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
ip vpn-instance vpn1
ipv4-family
route-distinguisher 100:1
#
ip vpn-instance vpn2
ipv4-family
route-distinguisher 200:1
#
firewall zone trust_a
priority 15
#
firewall zone trust_b
priority 30
#
firewall zone untrust_a
priority 1
#
firewall zone untrust_b
priority 5
#
firewall interzone trust_a untrust_a
firewall enable
#
firewall interzone trust_b untrust_b
firewall enable
#
firewall blacklist enable
firewall blacklist 10.3.1.2 vpn-instance vpn1
#
interface GigabitEthernet1/0/0
```

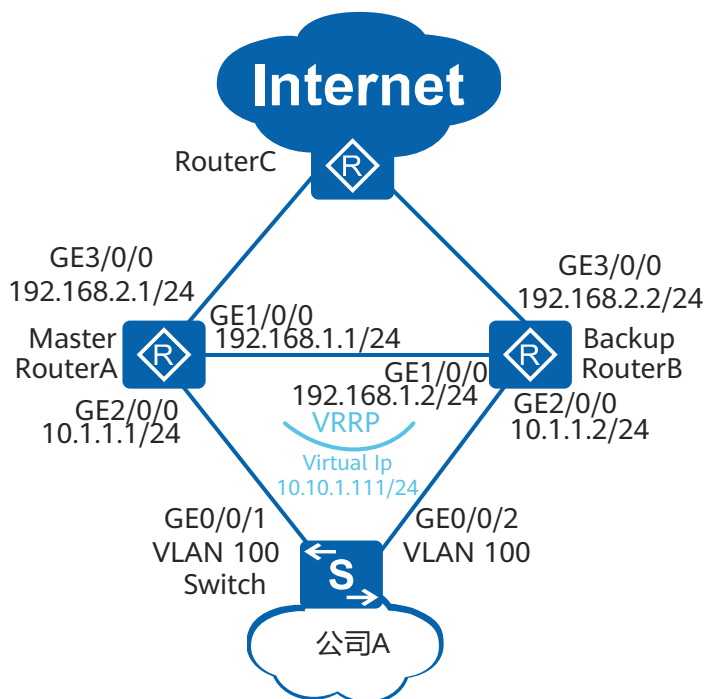
```
ip binding vpn-instance vpn1
ip address 10.1.1.1 255.255.255.0
zone trust_a
#
interface GigabitEthernet2/0/0
ip binding vpn-instance vpn2
ip address 10.2.1.1 255.255.255.0
zone trust_b
#
interface GigabitEthernet3/0/0
ip binding vpn-instance vpn1
ip address 10.3.1.1 255.255.255.0
zone untrust_a
#
interface GigabitEthernet4/0/0
ip binding vpn-instance vpn2
ip address 10.4.1.1 255.255.255.0
zone untrust_b
#
return
```

6.18.5 配置防火墙主备示例

组网需求

公司A基于确保内部网络安全性的考虑，在内外网络之间部署了防火墙。由于防火墙设备是所有信息流都必须通过的单一节点，故一旦防火墙设备出现故障所有信息流都会中断。为了增强网络的可靠性，保证当防火墙设备出现故障时不中断网络，公司A利用两台设备实现防火墙主备功能，如图6-26所示。

图 6-26 配置防火墙主备示例



配置思路

正常情况下，公司A内的用户主机以RouterA为默认网关接入Internet，当RouterA出现故障时，RouterB接替RouterA继续进行工作。具体配置思路如下：

1. 配置各设备接口IP地址及路由协议，以保证各设备间网络层连通。
2. 在RouterA和RouterB上分别配置防火墙功能，实现公司内外网的安全隔离。
3. 在RouterA和RouterB上配置VRRP备份组。其中，RouterA上配置较高优先级，作为主用设备承担流量转发；RouterB上配置较低优先级，作为备用设备。
4. 在RouterA和RouterB上配置双机热备份功能，将RouterA上的业务信息通过备份链路批量备份和实时备份到RouterB上，保证在主设备故障时业务能够不中断地顺利切换到备份设备。
5. 在RouterA和RouterB上分别使能防火墙主备功能，实现当主用防火墙设备RouterA出现故障时，备用防火墙设备RouterB启动防火墙功能，以保证网络的不间断运行。

操作步骤

步骤1 配置设备间的网络互连。

配置设备各接口的IP地址，以RouterA为例。RouterB的配置与之类似，详见配置文件。

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] interface gigabitethernet 1/0/0
[RouterA-GigabitEthernet1/0/0] ip address 192.168.1.1 24
[RouterA-GigabitEthernet1/0/0] quit
[RouterA] interface gigabitethernet 2/0/0
[RouterA-GigabitEthernet2/0/0] ip address 10.1.1.1 24
[RouterA-GigabitEthernet2/0/0] quit
[RouterA] interface gigabitethernet 3/0/0
[RouterA-GigabitEthernet3/0/0] ip address 192.168.2.1 24
[RouterA-GigabitEthernet3/0/0] quit
```

配置Switch的二层透传功能。

```
<Huawei> system-view
[Huawei] sysname Switch
[Switch] vlan 100
[Switch-vlan100] quit
[Switch] interface gigabitethernet 0/0/1
[Switch-GigabitEthernet0/0/1] port hybrid pvid vlan 100
[Switch-GigabitEthernet0/0/1] port hybrid untagged vlan 100
[Switch-GigabitEthernet0/0/1] quit
[Switch] interface gigabitethernet 0/0/2
[Switch-GigabitEthernet0/0/2] port hybrid pvid vlan 100
[Switch-GigabitEthernet0/0/2] port hybrid untagged vlan 100
[Switch-GigabitEthernet0/0/2] quit
```

步骤2 配置防火墙功能。

在RouterA上配置防火墙功能，RouterB的配置与之类似，详见配置文件。

```
[RouterA] firewall zone trust
[RouterA-zone-trust] priority 15
[RouterA-zone-trust] quit
[RouterA] firewall zone untrust
[RouterA-zone-untrust] priority 1
[RouterA-zone-untrust] quit
[RouterA] firewall interzone trust untrust
[RouterA-interzone-trust-untrust] firewall enable
[RouterA-interzone-trust-untrust] quit
```

在RouterA上将接口加入安全区域，RouterB的配置与之类似，详见配置文件。

```
[RouterA] interface gigabitethernet 1/0/0
[RouterA-GigabitEthernet1/0/0] zone untrust
[RouterA-GigabitEthernet1/0/0] quit
[RouterA] interface gigabitethernet 2/0/0
[RouterA-GigabitEthernet2/0/0] zone trust
[RouterA-GigabitEthernet2/0/0] quit
[RouterA] interface gigabitethernet 3/0/0
[RouterA-GigabitEthernet3/0/0] zone untrust
[RouterA-GigabitEthernet3/0/0] quit
```

步骤3 配置VRRP备份组。

在RouterA上创建VRRP备份组1，配置RouterA在该备份组中的优先级为120。

```
[RouterA] interface gigabitethernet 2/0/0
[RouterA-GigabitEthernet2/0/0] vrrp vrid 1 virtual-ip 10.1.1.111
[RouterA-GigabitEthernet2/0/0] vrrp vrid 1 priority 120
[RouterA-GigabitEthernet2/0/0] quit
```

在RouterB上创建VRRP备份组1，其在该备份组中的优先级为缺省值100。

```
[RouterB] interface gigabitethernet 2/0/0
[RouterB-GigabitEthernet2/0/0] vrrp vrid 1 virtual-ip 10.1.1.111
[RouterB-GigabitEthernet2/0/0] quit
```

步骤4 配置双机热备份功能，并使能防火墙主备功能。

在RouterA上创建HSB主备服务0，并配置其主备通道IP地址和端口号。

```
[RouterA] hsb-service 0
[RouterA-hsb-service-0] service-ip-port local-ip 192.168.1.1 peer-ip 192.168.1.2 local-data-port 10241
peer-data-port 10241
[RouterA-hsb-service-0] quit
```

在RouterB上创建HSB主备服务0，并配置其主备通道IP地址和端口号。

```
[RouterB] hsb-service 0
[RouterB-hsb-service-0] service-ip-port local-ip 192.168.1.2 peer-ip 192.168.1.1 local-data-port 10241
peer-data-port 10241
[RouterB-hsb-service-0] quit
```

在RouterA上创建HSB备份组0，并配置其绑定HSB主备服务0和VRRP备份组1。
RouterB的配置与之类似，详见配置文件。

```
[RouterA] hsb-group 0
[RouterA-hsb-group-0] bind-service 0
[RouterA-hsb-group-0] track vrrp vrid 1 interface gigabitethernet 2/0/0
[RouterA-hsb-group-0] quit
```

在RouterA上使能防火墙主备功能，RouterB的配置与之类似，详见配置文件。

```
[RouterA] hsb-service-type firewall hsb-group 0
```

在RouterA上使能HSB备份组0，使HSB备份组的相关配置生效。RouterB的配置与之类似，详见配置文件。

```
[RouterA] hsb-group 0
[RouterA-hsb-group-0] hsb enable
[RouterA-hsb-group-0] quit
```

步骤5 验证配置结果。

完成上述配置以后，在RouterA和RouterB上执行**display hsb-group group-index**命令，查看HSB备份组的运行情况。RouterA和RouterB上的显示信息如下。

```
<RouterA> display hsb-group 0
Hot Standby Group Configuration:
```



```
-----
HSB-group ID      : 0
Vrrp Group ID     : 1
Vrrp Interface    : GigabitEthernet2/0/0
Service Index     : 0
Group Vrrp Status  : Master
Group Status      : Active
Group Backup Process : Realtime
Peer Group Device Name : Router
Peer Group Software Version : V300R021
Group Backup Modules : Firewall
<RouterB> display hsb-group 0
Hot Standby Group Configuration:
-----
HSB-group ID      : 0
Vrrp Group ID     : 1
Vrrp Interface    : GigabitEthernet2/0/0
Service Index     : 0
Group Vrrp Status  : Backup
Group Status      : Inactive
Group Backup Process : Realtime
Peer Group Device Name : Router
Peer Group Software Version : V300R021
Group Backup Modules : Firewall
```

在RouterA的接口GE2/0/0上执行**shutdown**命令，模拟RouterA出现故障。

```
[RouterA] interface gigabitethernet 2/0/0
[RouterA-GigabitEthernet2/0/0] shutdown
[RouterA-GigabitEthernet2/0/0] quit
```

在RouterB上执行**display hsb-group group-index**命令查看HSB备份组状态信息，可以看到RouterB的状态是Master。

```
<RouterB> display hsb-group 0
Hot Standby Group Configuration:
-----
Hsb-group ID      : 0
Vrrp Group ID     : 1
Vrrp Interface    : GigabitEthernet2/0/0
Service Index     : 0
Group Vrrp Status  : Master
Group Status      : Independent
Group Backup Process : Realtime
Peer Group Device Name : Router
Peer Group Software Version : V300R021
Group Backup Modules : Firewall
```

----结束

配置文件

- RouterA的配置文件

```
#
sysname RouterA
#
hsb-service-type firewall hsb-group 0
#
interface GigabitEthernet1/0/0
ip address 192.168.1.1 255.255.255.0
zone untrust
#
interface GigabitEthernet2/0/0
ip address 10.1.1.1 255.255.255.0
vrrp vrid 1 virtual-ip 10.1.1.111
vrrp vrid 1 priority 120
zone trust
#
```

```
interface GigabitEthernet3/0/0
 ip address 192.168.2.1 255.255.255.0
 zone untrust
#
hsb-service 0
 service-ip-port local-ip 192.168.1.1 peer-ip 192.168.1.2 local-data-port 10241 peer-data-port 10241
#
firewall zone trust
 priority 15
#
firewall zone untrust
 priority 1
#
firewall interzone trust untrust
 firewall enable
#
hsb-group 0
 track vrrp vrid 1 interface GigabitEthernet2/0/0
 bind-service 0
 hsb enable
#
return
```

- RouterB的配置文件

```
#
sysname RouterB
#
hsb-service-type firewall hsb-group 0
#
interface GigabitEthernet1/0/0
 ip address 192.168.1.2 255.255.255.0
 zone untrust
#
interface GigabitEthernet2/0/0
 ip address 10.1.1.2 255.255.255.0
 vrrp vrid 1 virtual-ip 10.1.1.111
 zone trust
#
interface GigabitEthernet3/0/0
 ip address 192.168.2.2 255.255.255.0
 zone untrust
#
firewall zone trust
 priority 15
#
firewall zone untrust
 priority 1
#
firewall interzone trust untrust
 firewall enable
#
hsb-service 0
 service-ip-port local-ip 192.168.1.2 peer-ip 192.168.1.1 local-data-port 10241 peer-data-port 10241
#
hsb-group 0
 track vrrp vrid 1 interface GigabitEthernet2/0/0
 bind-service 0
 hsb enable
#
return
```

- Switch的配置文件

```
#
sysname Switch
#
vlan batch 100
#
interface GigabitEthernet0/0/1
 port hybrid pvid vlan 100
 port hybrid untagged vlan 100
```

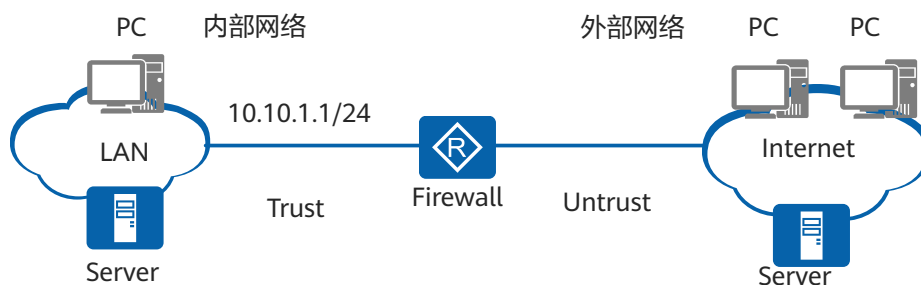
```
#  
interface GigabitEthernet0/0/2  
port hybrid pvid vlan 100  
port hybrid untagged vlan 100  
#  
return
```

6.18.6 配置通过端口过滤防火墙典型示例

组网需求

当设备位于内部网络和外部网络之间，同时为设备与内部网络、外部网络相连的接口分别配置不同网段的IP地址，并重新规划原有的网络拓扑结构。如图1所示，规划了2个安全区域：Trust区域和Untrust区域，设备的Trust区域接口与公司内部网络相连，Untrust区域接口与外部网络相连。需要注意的是，Trust区域接口和Untrust区域接口分别处于两个不同的子网中。

图 6-27 配置通过端口过滤防火墙组网图



配置思路

采用如下思路配置端口过滤防火墙：

1. 配置安全区域和安全域间。
2. 将接口加入安全区域。
3. 配置ACL。
4. 在安全域间配置基于ACL的包过滤。

操作步骤

步骤1 在Router上配置安全区域和安全域间。

```
<Huawei> system-view  
[Huawei] firewall zone trust  
[Huawei-zone-trust] priority 10  
[Huawei-zone-trust] statistics ip enable inzone  
[Huawei-zone-trust] statistics connect-number ip range 10.10.1.1 10.10.1.1 inzone tcp high 200 low 100 //配置设备对安全区域的IP地址的入方向TCP报文的流量统计阈值。其中，上限阈值为200，下限阈值为100。  
[Huawei-zone-trust] statistics ip enable outzone  
[Huawei-zone-trust] statistics connect-number ip range 10.10.1.1 10.10.1.1 outzone tcp high 200 low 100 //配置设备对安全区域的IP地址的出方向TCP报文的流量统计阈值。其中，上限阈值为200，下限阈值为100。  
[Huawei-zone-trust] quit
```

```
[Huawei] firewall zone untrust
[Huawei-zone-untrust] priority 5
[Huawei-zone-untrust] quit
[Huawei] firewall interzone trust untrust
[Huawei-interzone-trust-untrust] firewall enable
[Huawei-interzone-trust-untrust] quit
```

步骤2 在Router上将指定接口加入安全区域。

```
[Huawei] interface gigabitethernet 0/0/0
[Huawei-GigabitEthernet0/0/0] zone trust
[Huawei-GigabitEthernet0/0/0] quit
[Huawei] interface gigabitethernet 0/0/5
[Huawei-GigabitEthernet0/0/5] zone untrust
[Huawei-GigabitEthernet0/0/5] quit
```

步骤3 在Router上配置ACL。

```
[Huawei] acl 3010
[Huawei-acl-adv-3010] rule 5 permit ip
[Huawei-acl-adv-3010] quit
```

步骤4 在Router上配置包过滤。

```
[Huawei] firewall interzone trust untrust
[Huawei-interzone-trust-untrust] packet-filter 3010 inbound
[Huawei-interzone-trust-untrust] quit
```

步骤5 验证配置结果。

在Router上执行**display firewall interzone [zone-name1 zone-name2]**命令，结果如下。

```
[Huawei] display firewall interzone trust untrust
interzone trust untrust
firewall enable
packet-filter default deny inbound
packet-filter default permit outbound
packet-filter 3010 inbound
```

----结束

配置文件

Router的配置文件

```
#
interface Gigabitethernet 0/0/0
 zone trust
interface Gigabitethernet 0/0/5
 zone untrust
#
acl 3010
 rule 5 permit ip
#
firewall zone trust
 priority 10
 statistics ip enable inzone
 statistics connect-number ip range 10.10.1.1 10.10.1.1 inzone tcp high 200 low 100
 statistics ip enable outzone
 statistics connect-number ip range 10.10.1.1 10.10.1.1 outzone tcp high 200 low 100
#
firewall zone untrust
 priority 5
#
firewall interzone trust untrust
 firewall enable
 packet-filter 3010 inbound
#
return
```

6.19 防火墙 FAQ

6.19.1 如何清除、查看防火墙和 NAT 流表

在系统视图下执行命令**reset session all**，可以清除防火墙和NAT流表信息。

在任意视图下执行命令**display session**，可以查看防火墙和NAT流表信息。

6.19.2 如何查看包过滤防火墙配置的 ACL 命中计数

1. 在系统视图下，执行命令**traffic classifier classifier-name**，创建流分类并进入流分类视图。执行命令**if-match acl { acl-number / acl-name }**配置流分类的匹配规则。
2. 在系统视图下，执行命令**traffic behavior behavior-name**，创建一个流行为并进入流行为视图。执行命令**statistic enable**，使能流量统计功能。
3. 在系统视图下，执行命令**traffic policy policy-name**，创建流策略并进入流策略视图。执行命令**classifier classifier-name behavior behavior-name**，在策略中关联流分类和动作。
4. 在需要计数的端口视图下，执行命令**traffic-policy policy-name inbound**。
5. 执行命令**display traffic policy statistics interface interface-type interface-number inbound verbose rule-base**，查看相关接口上的包过滤防火墙配置的ACL命中计数情况。

6.19.3 AR 防火墙 ASPF 支持哪些协议

支持如下几种协议：

- FTP（File Transfer Protocol）
- SIP（Session Initiation Protocol）
- RTSP（Real Time Streaming Protocol）

6.19.4 黑名单（防火墙）产生方式

黑名单产生方式包括：

- 手动配置的静态黑名单
- 扫描攻击产生的动态黑名单

7 深度安全防御配置

设备通过安全策略实现了基于应用层的深度安全防御，保护用户不受多种网络威胁的侵扰。

7.1 安全策略

设备通过安全策略可以实现对业务流量的转发和内容安全的一体化检测及处理。

7.2 IPS配置

IPS是一种安全机制，它通过监控或者分析系统事件来检测入侵行为，并通过一定的响应方式实时的中止入侵行为。

7.3 URL过滤配置

通过配置URL过滤，可以对用户访问的URL进行控制，允许或禁止用户访问某些网页，以达到规范上网行为的目的。

7.4 反病毒配置（AV）

7.1 安全策略

设备通过安全策略可以实现对业务流量的转发和内容安全的一体化检测及处理。

7.1.1 安全策略简介

介绍设备安全策略的定义和特点。

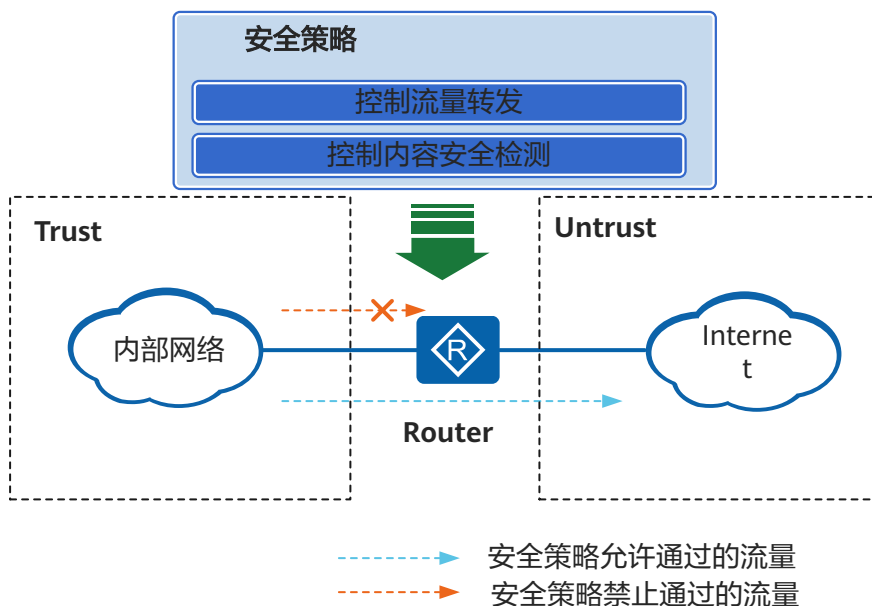
随着网络的发展，层出不穷的新应用虽然给人们的网络生活带来了更多的便利，但是同时也带来更多的安全风险。现在内网主机在访问Internet的过程中，很有可能无意中从外网引入蠕虫、木马及其他病毒，造成企业机密数据泄露，对企业经营造成巨大损失。为了保护公司内部网络安全，企业有必要在控制流量的源和目的的基础上，再对流量传输的真实内容进行深入的识别和监控。但是传统的单包检测机制只能对单个报文的安全性进行分析，这样无法防范在一次正常网络访问的过程中发生的缓冲区溢出攻击、木马、蠕虫等网络威胁。安全策略不仅可以对网络流量进行转发，还可以对网络流量进行内容安全一体化检测。

内容安全一体化检测是指使用设备的一体化检测引擎对一条流量的内容只进行一次检测和处理，就能实现包括IPS、URL过滤在内的内容安全功能。由于一体化检测的高效性，用户往往可以通过配置较宽泛的安全策略条件来匹配一类流量，然后再通过各种内容安全功能来保证网络安全。

如图7-1所示，设备能够识别出流量的属性，并将流量的属性与安全策略的条件进行匹配。如果所有条件都匹配，则此流量成功匹配安全策略，否则允许流量通过。流量匹配安全策略后，设备将会对流量进行内容安全检测，并根据检测结果执行相应的动作。

- 如果检测结果为“允许”或“告警”，则允许流量通过。检测结果为“告警”时设备会记录日志。
- 如果检测结果为“禁止”，则禁止流量通过。

图 7-1 Router 的安全策略



7.1.2 安全策略原理描述

介绍设备安全策略的实现原理。

设备的安全策略

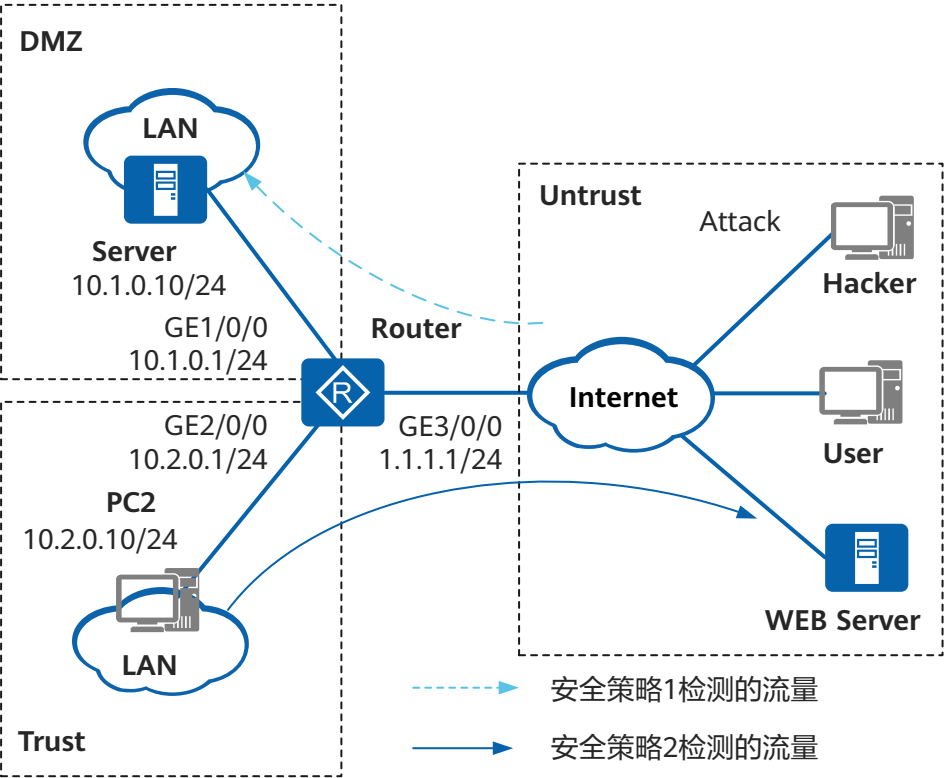
传统防火墙可以通过IP地址和协议进行流量控制。随着网络的发展，层出不穷的新应用虽然给人们的网络生活带来了更多的便利，但是同时也带来更多的安全风险。最为典型是随着网页技术的发展，越来越多不同风险级别的业务借用HTTP和HTTPS协议运行在80和443端口之上，例如网页即时通讯、网页游戏、视频网站、网页聊天等等。同时，由于远程办公、移动办公等新兴的办公形式的出现，同一使用者所使用的主机IP地址可能随时在发生变化，通过IP地址进行流量控制已经不能满足现代网络的需求。所以企业的网络安全管理，有必要在控制流量的源和目的的基础上，再对流量传输的真实内容进行深入的识别和监控。

设备通过安全策略可以实现基于应用层的流量转发控制，还可以对流量的内容进行安全检测和处理。设备的安全策略可以更好的适应新时代网络的特点，满足新时代网络的需求。

如图7-2所示，通过安全策略1应用入侵防御系统IPS（Intrusion Prevention System）功能，可以保护内部网络的服务器，避免受到来自Internet的攻击。通过安全策略2应

用IPS、URL过滤功能，既允许安全区域Trust的用户浏览Internet网页，又可以对浏览的内容进行检测，防止病毒和黑客的入侵。

图 7-2 设备的安全策略



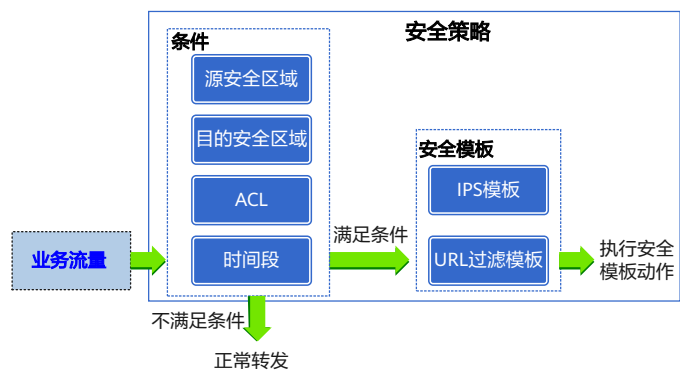
Router的安全策略体现了以下优势：

- 能够在不同的安全区域应用对应的安全策略，使网络的管理更加灵活和可视。
- 能够有效区分协议（例如HTTP）承载的不同应用（例如网页即时通讯、网页游戏等），使网络的管理更加精细。
- 能够通过安全策略实现内容安全检测，阻断病毒、黑客等的入侵，更好的保护内部网络。

设备安全策略处理流程

设备的安全策略处理流程如图7-3所示。

图 7-3 设备安全策略的处理流程

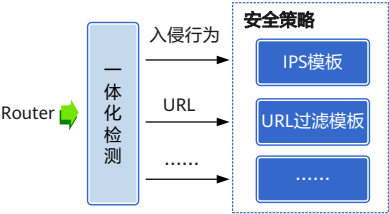


流量通过Router时，安全策略的处理流程如下：

1. Router会对收到的流量进行检测，检测出流量的属性，包括：源安全区域、目的安全区域、ACL（源地址、目的地址、源端口、目的端口、协议类型）和时间段。

2. Router将流量的属性与安全策略的条件进行匹配。如果所有条件都匹配，则继续进行步骤3的处理，否则允许此流量通过。
 3. 如果流量成功匹配了安全策略的条件，则Router会判断安全策略是否引用了安全模板。如果引用了安全模板，则继续进行步骤4的处理；如果没有引用安全模板，则允许此流量通过。
 4. 如果安全策略引用了安全模板，则Router会对流量进行内容安全的一体化检测。一体化检测是指根据安全模板的条件对流量的内容进行一次检测，根据检测的结果执行安全模板的动作。如果其中一个安全模板阻断此流量，则Router阻断此流量。如果所有的安全模板都允许此流量转发，则Router允许此流量转发。
- 如图7-4所示，Router的所有内容安全功能通过安全策略引用的安全模板实现，只需要进行一次检测和处理，系统性能大幅度提升。

图 7-4 Router 一体化检测



安全策略可以引用的安全模板及其功能如表7-1所示。

表 7-1 安全模板及功能

安全模板	功能
IPS配置	入侵防御通过比较流量内容与入侵防御特征库来实现攻击检测，有效防御来自应用层的攻击，例如缓冲区溢出攻击、木马、蠕虫等。
URL过滤配置	URL过滤可以对用户的URL请求进行管控，允许或禁止用户访问某些网页资源，达到规范上网行为的目的。

安全模板的搭配使用

合理搭配使用安全模板既可以实现强大的内容安全防护功能，又可以避免系统资源的浪费。

下面介绍一些安全模板搭配使用的技巧，如表7-2所示。

表 7-2 安全模板搭配使用

功能	作用	安全模板
服务器防护	保证提供对外访问的服务器免受病毒和入侵行为的危害。	● IPS：防御对服务器的应用层攻击。
Web访问防护	保证内网用户访问Web网站和下载文件时免受病毒和入侵行为的危害。	● IPS：阻断Web访问时的入侵行为。 ● URL过滤：过滤掉非法网站和恶意网站，降低感染病毒和受到攻击的风险。

7.1.3 安全策略应用场景

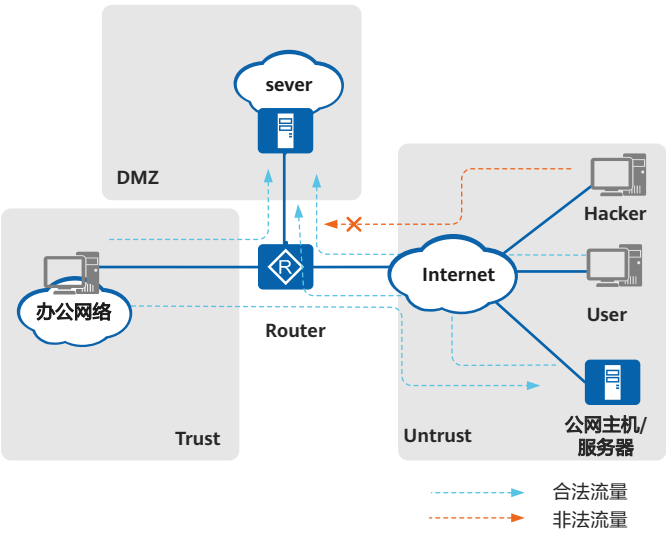
介绍安全策略的应用场景。

网络中存在多种业务流量，针对不同的业务流量，设备上可以配置多条安全策略。通过安全策略对安全区域间的流量进行检测，保护公司内部网络。

如图7-5所示，当Router作为一个大中型企业网络的边界安全网关时，安全策略的部署如下：

- 公司将办公网络、服务器网络、外部网络划分到不同安全区域，通过安全策略对安全区域间的流量进行检测，保护公司内部网络。
- 根据公司对外提供的网络服务的类型配置安全策略的内容安全功能。例如针对所有服务器开启IPS。
- 针对内网员工访问外部网络的行为，配置URL过滤安全功能，可以防止员工在工作时间随意访问与工作无关的网站而影响了工作效率。

图 7-5 安全策略应用在内外网之间示意图



7.2 IPS 配置

IPS是一种安全机制，它通过监控或者分析系统事件来检测入侵行为，并通过一定的响应方式实时的中止入侵行为。

7.2.1 IPS 简介

介绍IPS的定义、由来和作用。

定义

入侵防御系统IPS（Intrusion Prevention System）是一种安全机制，通过分析网络流量可以检测出入侵行为（包括缓冲区溢出攻击、木马、蠕虫等），提供一种主动的、实时的防护，对网络深层攻击行为进行准确的分析判断，阻止漏洞攻击的恶意流量，为企业网络提供“虚拟补丁”，从而保护企业信息系统和网络架构免受侵害。

目的

随着网络的发展，层出不穷的新应用虽然给人们的网络生活带来了更多的便利，但是同时也带来更多的安全风险。在访问Internet的过程中，很有可能无意中从外网引入蠕虫、木马及其他病毒，造成企业机密数据泄露，对企业经营造成巨大损失。所以企业的网络安全管理，有必要在控制流量的源和目的的基础上，再对流量传输的真实内容进行深入的识别和监控。

通过IPS可以防护应用层的攻击或入侵，例如缓冲区溢出攻击、木马、蠕虫等。

优势

入侵防御是种既能发现又能阻止入侵行为的新安全防御技术。通过检测发现网络入侵后，能自动丢弃入侵报文或者阻断攻击源，从而从根本上避免攻击行为。入侵防御的主要优势有如下几点。

- 实时阻断攻击：设备采用直路方式部署在网络中，能够在检测到入侵时，实时对入侵活动和攻击性网络流量进行拦截，把其对网络的入侵降到最低。
- 深层防护：由于新型的攻击都隐藏在TCP/IP协议的应用层里，入侵防御能检测报文应用层的内容，还可以对网络数据流重组进行协议分析和检测，并根据攻击类型、策略等来确定哪些流量应该被拦截。
- 全方位防护：入侵防御可以提供针对蠕虫、病毒、木马、僵尸网络、间谍软件、广告软件、CGI（Common Gateway Interface）攻击、跨站脚本攻击、注入攻击、目录遍历、信息泄露、远程文件包含攻击、溢出攻击、代码执行、拒绝服务、扫描工具等攻击的防护措施，全方位防御各种攻击，保护网络安全。
- 内外兼防：入侵防御不但可以防止来自于企业外部的攻击，还可以防止发源于企业内部的攻击。系统对经过的流量都可以进行检测，既可以对服务器进行防护，也可以对客户端进行防护。
- 不断升级，精准防护：入侵防御特征库会持续的更新，以保持最高水平的安全性。您可以从升级中心定期升级设备的特征库，以保持入侵防御的持续有效性。
- WEB安全防护：AR内置深度安全引擎，支持检测SQL注入、XSS攻击、网页挂马等WEB安全威胁，为企业提供WEB安全的防护能力。

与传统 IDS（Intrusion Detection System）的不同

总体上说，IDS对那些异常的、可能是入侵行为的数据进行检测和报警，告知使用者网络中的实时状况，并提供相应的解决、处理方法，是一种侧重于风险管理的安全功能。而入侵防御对那些被明确判断为攻击行为，会对网络、数据造成危害的恶意行为进行检测，并实时终止，降低或是减免使用者对异常状况的处理资源开销，是一种侧重于风险控制的安全功能。

入侵防御技术在传统IDS的基础上增加了强大的防御功能：

- 传统防火墙很难对基于应用层的攻击进行预防和阻止。入侵防御设备能够有效防御应用层攻击。
而由于重要数据夹杂在过多的一般性数据中，IDS很容易忽视真正的攻击，误报和漏报率居高不下，日志和告警过多。而入侵防御功能则可以对报文层层剥离，进行协议识别和报文解析，对解析后的报文分类并进行专业的特征匹配，保证了检测的精确性。
- IDS设备只能被动检测保护目标遭到何种攻击。为阻止进一步攻击行为，它只能通过响应机制报告给防火墙，由防火墙来阻断攻击。

入侵防御是一种主动积极的入侵防范阻止系统。检测到攻击企图时会自动将攻击包丢掉或将攻击源阻断，有效地实现了主动防御功能。

7.2.2 IPS 原理描述

介绍IPS的实现原理。

基本概念

在了解入侵行为检测的原理之前，您需要知道IPS特征库、IPS签名以及安全中心平台的作用：

- IPS特征库：华为公司通过分析各种常见入侵行为形成了IPS特征库，该库对各种常见的入侵行为特征进行了定义，同时为每种入侵行为特征都分配了一个唯一的入侵行为ID。设备加载IPS特征库后，即可识别出IPS特征库里已经定义过的入侵行为。
- 安全中心平台：域名为sec.huawei.com，华为公司部署的服务器，可以为购买License的客户提供IPS特征库升级服务，升级IPS特征库请参见[“IPS特征库升级”](#)。
- IPS签名

IPS签名用来描述网络中存在的该入侵行为的特征，及设备需要对其采取的动作。设备通过将报文内容和IPS签名进行比较，就可以检测和防范该入侵行为攻击。

IPS签名包括预定义签名和自定义签名。

– 预定义签名

预定义签名是系统预先定义的大量签名。预定义签名已经预先设置了匹配该签名的签名动作为阻断或告警。管理员可以根据预定义签名对入侵行为进行防范和阻断。

设备出厂时已加载了预定义签名库，即IPS特征库。为了能够及时识别出最新的入侵行为，用户可以购买License并激活，IPS特征库会定期进行更新，这样就能够不断地从安全中心平台获取最新的预定义签名，以保证对新的入侵行为及时响应。

– 自定义签名

自定义签名是管理员根据网络流量特点对特定的入侵行为自行定义的签名。

- 在预定义签名以外，管理员出于某种原因要阻止或记录特定的行为时创建的。比如，员工使用聊天软件时，某些行为（并非预定义签名中检测的入侵行为，如传送可执行文件容易引起病毒传播）需要被阻断，管理员则可根据行为特征来创建自定义签名，动作为阻断，引入到配置文件中。
- 当网络中某些入侵来临，而IPS特征库尚未更新的情况下，管理员分析入侵特征后也可创建自定义签名。而当IPS特征库更新后，便可使用预定义签名。

用户可以通过签名过滤器对预定义签名进行管理，通过例外签名对预定义签名、自定义签名进行管理。

- 签名过滤器

由于设备升级特征库后会存在大量签名，而这些签名是没有进行分类的，且有些签名所包含的特征本网络中不存在，需过滤出去，故设置了签名过滤器进行管理。管理员分析本网络中常出现的威胁的特征，并将含有这些特征的签名通过签名过滤器提取出来，防御本网络中可能存在的威胁。

签名过滤器是满足指定过滤条件的签名集合。签名过滤器的过滤条件包括：签名的类别、对象、协议、严重性、操作系统等。只有同时满足所有过滤条件的签名才能加入签名过滤器中。例如，当只需要对HTTP类型的报文进行入侵防御，可以通过过滤条件只加入HTTP协议的签名。

签名过滤器的动作分为阻断、告警和采用签名的缺省动作。签名过滤器的动作优先级高于签名缺省动作，当签名过滤器的动作不采用签名缺省动作时，以签名过滤器设置的动作为准。

各签名过滤器之间存在优先关系（按照配置顺序，先配置的优先）。如果一个安全配置文件中的两个签名过滤器包含同一个签名，当报文命中此签名后，设备将根据优先级高的签名过滤器的动作对报文进行处理。

- 例外签名

为了方便管理，签名过滤器会批量过滤出签名。如果管理员需要将某些签名设置为与签名过滤器不同的动作时，可将这些签名引入到例外签名中，并单独配置动作。例如，当管理员从日志中查看到某个攻击事件需要阻断，可以将匹配此攻击的签名加入到例外签名中，并设置动作为阻断。

例外签名的动作分为阻断、告警和放行。

例外签名的动作优先级高于签名过滤器。如果一个签名同时命中例外签名和签名过滤器，则以例外签名的动作为准。

例如，签名过滤器中过滤出一批符合条件的签名，且动作统一设置为阻断。但是员工经常使用的某款自研软件却被拦截了。观察日志发现，用户经常使用的该款自研软件命中了签名过滤器中某个签名，被误阻断了。此时管理员可将此签名引入到例外签名中，并修改动作为放行。

IPS 特征库升级

IPS特征库的升级支持增量的在线升级方式，并且在升级的过程中不影响系统的正常业务。IPS特征库升级完成后，系统自动切换IPS特征库版本，不需要重启设备。如果在IPS特征库版本升级过程中发生异常而导致升级失败，系统会自动回退到上一个IPS库版本，也不会影响系统的正常业务。

为了保证对新的入侵行为及时响应，安全中心平台上的IPS特征库会实时更新。用户可以选择通过在线升级或者本地升级的方式，从安全中心平台获取最新的IPS特征库升级包，以达到最佳的入侵防御效果。

- 在线升级
 - 如果设备可以正常访问安全中心平台，可以通过安全中心平台进行在线升级。在线升级支持定时升级和立即升级。
 - 定时升级：用户只需要指定定时升级的时间，就能实现IPS特征库的及时自动更新和手动更新。为了避免由于网络状况不好造成的升级失败，建议用户将定时升级的时间设置在网络流量较小的时间进行。
 - 立即升级：当管理员发现网络上出现新的攻击行为，而设备的定时升级时间尚未到达时，立即执行升级操作，让设备可以对新的攻击行为进行防御。
- 本地升级：当设备与安全中心平台之间网络不可达时，用户可以在能够访问安全中心平台的PC上，登录安全中心平台手工下载最新的IPS特征库升级包，然后通过FTP、TFTP或Web方式将升级文件上传至设备进行IPS特征库的更新。

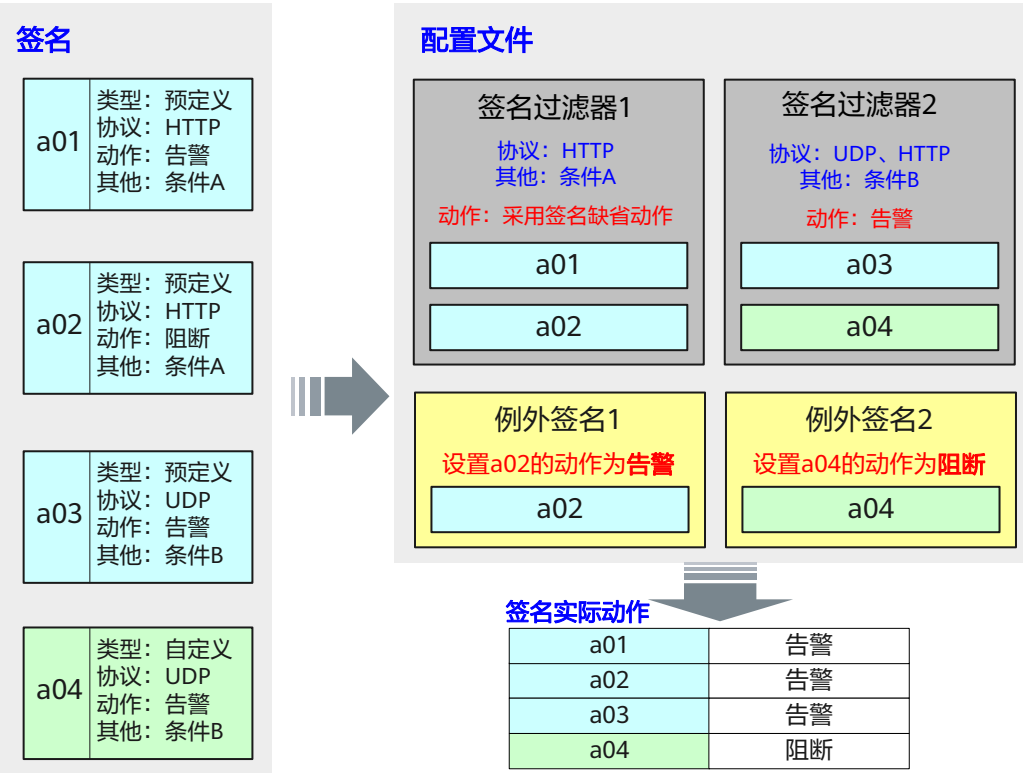
IPS 对数据流的处理

入侵防御配置文件包含多个签名过滤器和多个例外签名。

签名、签名过滤器、例外签名的关系如图7-6所示。假设设备中配置了3个预定义签名，分别为a01、a02、a03，且存在1个自定义签名a04。配置文件中创建了2个签名过滤器，签名过滤器1可以过滤出协议为HTTP、其他项为条件A的签名a01和a02，动作为使用签名缺省动作。签名过滤器2可以过滤出协议为HTTP和UDP、其他项为条件B的签名a03和a04，动作为告警。另外，2个配置文件中分别引入1个例外签名。例外签名1中，将签名a02的动作设置为告警；例外签名2中，将签名a04的动作设置为阻断。

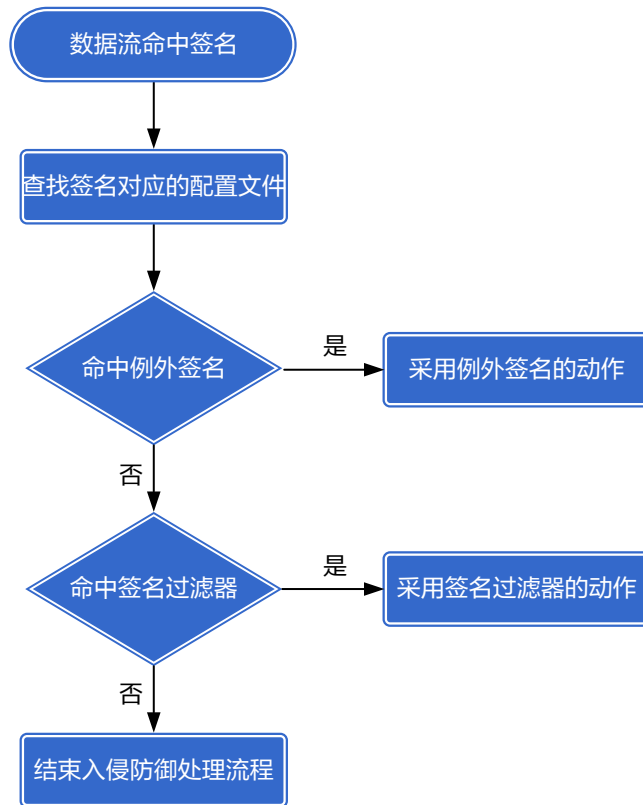
签名的实际动作由签名缺省动作、签名过滤器和例外签名的动作共同决定的，参见图7-6中的“签名实际动作”。

图 7-6 签名、签名过滤器、例外签名的关系



当数据流命中的安全策略中包含IPS配置文件时，设备将数据流送到IPS模块，并依次匹配IPS配置文件引用的签名。IPS对数据流的通用处理流程请参见图7-7。

图 7-7 IPS 对数据流的处理



说明

当数据流命中多个签名，对该数据流的处理方式如下：

- 如果这些签名的实际动作都为**告警**时，最终动作为**告警**。
- 如果这些签名中至少有一个签名的实际动作为**阻断**时，最终动作为**阻断**。

当数据流命中了多个签名过滤器时，设备会按照优先级最高的签名过滤器的动作来处理。

以图7-6中的配置为例，根据图7-7，设备对数据流处理过程如下：

数据流首先匹配例外签名，假设命中了例外签名1中的a02，则由于例外签名1的动作为**告警**，跳过并继续匹配签名过滤器。假设命中了签名过滤器2中的a04。签名过滤器2的动作为**阻断**，则对报文最终处理方式**为阻断**。

7.2.3 IPS 应用场景

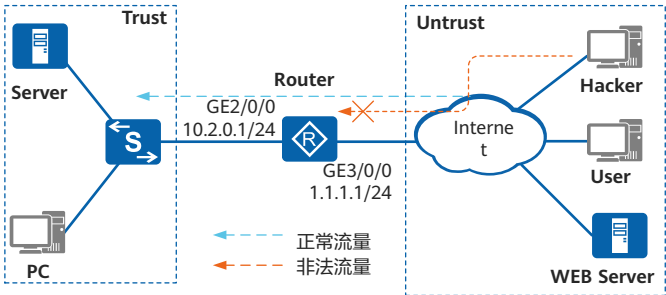
介绍IPS的应用场景。

7.2.3.1 使用 IPS 阻断入侵行为

如图7-8所示，Router作为企业出口网关。为了防御应用层攻击（例如缓冲区溢出攻击、木马和蠕虫等），保护内网主机不受外网病毒和入侵的威胁，提高企业网络的安

全性，可以在Router上部署IPS，使Router对安全区域间的流量进行检测。如果检测出流量中包含入侵行为，则可以对非法流量进行阻断；如果不是入侵行为，则允许流量正常通过。

图 7-8 IPS 典型应用场景



7.2.4 IPS 配置注意事项

涉及网元

无需其他网元配合。

License 支持

表 7-3 IPS 支持的 License 列表

系列	License支持情况
AR300&AR700系列	AR720和AR730无需获得License许可即可应用该功能。

表 7-4 升级 IPS 特征库支持的 License 列表

系列	License支持情况
AR300&AR700系列	需要购买如下License许可才能使用升级IPS特征库功能。 ● AR SOHO IPS服务时间1年

硬件依赖

表 7-5 IPS 硬件依赖

系列	特性支持情况
AR300&AR700系列	仅AR720和AR730支持IPS。

特性依赖和限制

在路由器上部署IPS特性时，需要注意：

- 设备支持入侵防御IPS功能，这些功能涉及采集或存储个人用户通信内容。本公司无法单方采集或存储用户通信内容。建议您只有在所适用法律法规允许的目的和范围内方可启用相应的功能。在使用、存储用户通信内容的过程中，您应采取足够的措施以确保用户的通信内容受到严格保护。
- 在报文来回路径不一致的组网环境中，可能无法有效检测到网络入侵。

7.2.5 IPS 缺省配置

介绍IPS的缺省配置。

IPS的缺省配置如表7-6所示。

表 7-6 IPS 缺省配置

参数	缺省值
安全策略	未配置。

参数	缺省值
IPS模板	设备缺省存在多个安全配置文件以适用于不同的应用场景，缺省的安全配置文件可以查看、复制或直接被安全策略引用，但是不可以修改或删除。 ● video_surveillance：包括所有签名，动作采用签名的缺省动作。适用于DNS、HTTP、FTP、TELNET、SSH、RTSP、SSL、UDP、TCP协议。适用于所有威胁类别。该配置文件适用于当设备部署在视频监控的场景。 ● strict：包括所有签名，动作为阻断。适用于所有协议。适用于所有威胁类别。该配置文件适用于需要设备阻断所有命中签名的报文场景。 ● web_server：包括所有签名，动作采用签名的缺省动作。适用于DNS、HTTP、FTP协议。适用于所有威胁类别。该配置文件适用于当设备部署在Web服务器前面的场景。 ● file_server：包括所有签名，动作采用签名的缺省动作。适用于DNS、SMB、NETBIOS、NFS、SUNRPC、MSRPC、FILE、TELNET协议。适用于所有威胁类别。该配置文件适用于当设备部署在File服务器前面的场景。 ● dns_server：包括所有签名，动作采用签名的缺省动作。适用于DNS协议。适用于所有威胁类别。该配置文件适用于当设备部署在DNS服务器前面的场景。 ● mail_server：包括所有签名，动作采用签名的缺省动作。适用于DNS、IMAP4、SMTP、POP3协议。适用于所有威胁类别。该配置文件适用于当设备部署在Mail服务器前面的场景。 ● inside_firewall：包括所有签名，动作采用签名的缺省动作。适用于所有协议。适用于所有威胁类别。该配置文件适用于当设备部署在防火墙里面的场景。 ● dmz：包括所有签名，动作采用签名的缺省动作。适用于除NETBIOS、NFS、SMB、TELNET和TFTP之外的所有协议。适用于所有威胁类别。该配置文件适用于当设备部署在DMZ区域前的场景。 ● outside_firewall：包括所有签名，动作采用签名的缺省动作。适用于所有协议。适用于除Scanner之外的威胁类别。该配置文件适用于当设备部署在防火墙外面的场景。 ● ids：包括所有签名，动作为告警。适用于所有协议。适用于所有威胁类别。该配置文件适用于当设备以IDS（旁路）模式部署时的通用场景。 ● default：包括所有签名，动作采用签名的缺省动作。适用于所有协议。适用于所有威胁类别。

参数	缺省值
	该配置文件适用于当设备以IPS（直路）模式部署时的通用场景。
IPS日志缓存功能	已使能。
IPS日志缓存输出时间	1分钟。

7.2.6 开启深度安全防御功能

背景信息

如果需要使用IPS功能、URL过滤或者AV反病毒功能，除购买对应License外，同时还需要通过执行**engine enable**命令开启深度安全防御功能。

开启深度安全功能后，如果需要关闭该功能，请执行命令**undo engine enable**并重启设备，关闭深度安全功能才生效。重启后，有关深度安全的配置将不存在。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**engine enable**，开启深度安全防御功能。

缺省情况下，系统未开启深度安全防御功能。

----结束

7.2.7 升级 IPS 特征库

介绍升级IPS特征库的方法。

前提条件

升级IPS特征库（预定义签名库）需要确保已购买支持IPS特征库升级服务的License并且在有效服务期内。

用户购买了带入侵防御升级功能的License后能够不断地从安全中心平台（缺省域名为sec.huawei.com）获取新的IPS特征库。

背景信息

为识别更多的入侵行为，提高系统的安全防护能力，在配置IPS功能之前，请先升级IPS特征库。

IPS特征库是IPS进行入侵防御检测的基础，IPS特征库中包括预定义的IPS签名。IPS签名用来描述网络中存在的攻击行为的特征，设备通过将报文内容和IPS签名进行比较来检测和防范攻击。如果某个数据流匹配了某个签名中的特征项时，设备可按照该签名的动作来处理数据流。预定义签名的内容是固定的，不能被创建或修改。

IPS特征库的升级方式有：

- 在线升级
当设备能访问安全中心平台时，可以配置通过安全中心平台进行在线升级。
- 本地升级
当设备无法访问安全中心平台时，用户可以在能够访问安全中心平台的PC上下载升级包，通过FTP或TFTP等方式将IPS特征库文件上传到设备上上进行本地升级。

说明

- 由于设备本身没有预装特征库，用户需要通过在线升级或本地升级的方式加载特征库。
- 当设备更换启动路径时，用户需要再次通过在线升级或本地升级的方式加载特征库。

操作步骤

- 在线升级
 - a. 执行命令**system-view**，进入系统视图。
 - b. （可选）执行命令**update server { domain domain-name | ip ip-address } [port port-number]**，配置升级服务器的IP地址或者域名。

缺省情况下，升级服务器的域名为sec.huawei.com，HTTP协议的端口号为80，HTTPS协议的端口号为443。
 - c. （可选）执行命令**update download-server aging-time age-time**，配置下载服务器的老化时间。缺省情况下，下载服务器的老化时间为7天。

说明

下载服务器的老化时间仅对HTTPS升级方式生效，对HTTP升级方式不生效。

- d. （可选）通过代理服务器访问升级服务器。
 - i. 执行命令**update proxy enable**，开启特征库代理升级功能。
缺省情况下，设备没有开启特征库代理升级功能。
 - ii. 执行命令**update proxy { domain domain-name | ip ip-address } [port port-number] [user user-name [password password]]**，配置代理服务器的IP地址或者域名。
- e. 确定在线升级方式
 - 通过安全中心平台进行在线升级
为保证设备能访问安全中心平台，需要配置动态域名解析功能。
 - 1) 执行命令**dns resolve**，启用DNS服务器的域名解析功能。
 - 2) 执行命令**dns server ip-address**，配置DNS服务器的IP地址。
- f. 定时升级
 - i. 执行命令**update schedule ips-sdb enable**，开启IPS特征库的定时升级功能。
缺省情况下，已开启IPS特征库定时升级功能。
 - ii. 执行命令**update schedule [{ daily | weekly { Mon | Tue | Wed | Thu | Fri | Sat | Sun } } time]**，配置IPS特征库定时在线下载时间。
如果未配置定时下载时间，则缺省在22:00~08:00之间随机选择一个时间作为每天进行定时升级的时间。
*time*建议设置为一天中设备流量最小的时间，例如凌晨6点前后。
 - iii. 配置IPS特征库安装方式

IPS特征库下载后，还需要在设备上安装才生效。用户可以选择是否使能安装确认功能，即定时升级的IPS特征库是否需要经过用户确认后再安装。

IPS特征库安装时涉及新旧IPS特征库的切换，可能影响入侵行为的检测，用户可以选择影响较小时启用安装确认功能。

- 用户确认后进行安装

- 1) 执行命令**update confirm ips-sdb enable**，使能安装确认功能，即定时下载的IPS特征库需要经过用户确认后再安装。

缺省情况下，关闭特征库安装确认功能，即设备下载升级文件后自动进行安装。

- 2) 执行命令**update apply ips-sdb**，安装下载的IPS特征库。

- 用户无需确认即直接安装

执行命令**undo update confirm ips-sdb enable**，去使能安装确认功能，即定时下载的IPS特征库进行自动安装，不需要经过用户确认。

- g. （可选）立即升级

用户一般可选择定时升级。如果发现网络上出现新的入侵行为，而设备的定时升级时间尚未达到时，用户可以执行立即升级。

- i. 执行命令**update online ips-sdb**，立即下载IPS特征库。
- ii. 执行命令**update apply ips-sdb**，安装下载的IPS特征库。

- 终止升级

在用户开始升级后，发现升级过程占用了较大网络资源，可以终止升级。

 说明

只有在下载阶段才可以终止升级。

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**update abort**，用来终止升级。

- 回退版本

如果升级后的特征库出现问题或不符合用户预期，用户可使用该命令回退到上一个版本。

 说明

进行版本回退前，建议先使用**display version ips-sdb**命令查看可回退版本信息，再决定是否要进行版本回退。如果不存在可回退版本，版本回退将失败，设备中仍然是回退前的版本。

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**update rollback ips-sdb**，回退IPS特征库到上一个版本。

- 本地升级

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**update local ips-sdb file filename**，进行本地升级IPS特征库。

 说明

本地升级不支持**终止升级**。

- 恢复出厂默认版本

说明

特征库恢复到出厂默认版本后，设备上其他所有IPS特征库均被删除。

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**update restore sdb-default ips-sdb**，将特征库恢复到出厂默认版本。

----结束

升级结果验证

- 执行命令**display engine information**，查看引擎的运行状态和特征库的版本信息。
- 执行命令**display version ips-sdb**，查看升级后IPS特征库的版本信息。
- 执行命令**display update status**，查看升级的状态。
- 执行命令**display update configuration**，查看升级配置信息。

7.2.8 配置 IPS

介绍IPS详细的配置过程。

7.2.8.1 （可选）配置 IPS 自定义签名

背景信息

自定义签名是管理员根据网络流量特点对特定的入侵行为自行定义的签名。

- 在预定义签名以外，管理员出于某种原因要阻止或记录特定的行为时创建的。比如，员工使用聊天软件时，某些行为（并非预定义签名中检测的入侵行为，如传送可执行文件容易引起病毒传播）需要被阻断，管理员则可根据行为特征来创建自定义签名，动作为阻断，引入到配置文件中。
- 当网络中某些入侵来临，而IPS特征库尚未更新的情况下，管理员分析入侵特征后也可创建自定义签名。而当IPS特征库更新后，便可使用预定义签名。

一个IPS自定义签名由多个规则组成，每条规则由多个检查项组成。

报文按照如下顺序进行签名匹配：设备按照配置先后顺序依次匹配各条规则，只要报文命中签名中至少一条规则即表示该报文命中此签名。当报文中一条规则中的所有检查项时，即表示该报文中命中了此规则。

说明

IPS自定义签名配置完成后，对设备上的安全策略都起作用。当在安全域间应用安全策略后，IPS自定义签名的配置立即生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**ips signature-id signature-id**，创建IPS自定义签名并进入IPS自定义签名视图。

缺省情况下，系统未创建IPS自定义签名。

步骤3 （可选）执行命令**name name**，配置IPS自定义签名的名称。

步骤4 （可选）执行命令**description description**，配置IPS自定义签名的描述信息。

缺省情况下，系统未配置IPS自定义签名的描述信息。

步骤5 配置IPS自定义签名的基本特征。

- 执行命令**target { both | client | server }**，配置IPS自定义签名的检测对象。
缺省情况下，IPS自定义签名的检测对象为客户端和服务端端的报文。
- 执行命令**severity { high | information | low | medium }**，配置IPS自定义签名的威胁等级。
缺省情况下，IPS自定义签名的威胁等级是high。
- 执行命令**protocol protocol-name**，配置IPS自定义签名的协议类型。
缺省情况下，IPS自定义签名的协议类型是HTTP。

说明

一个IPS自定义签名中只能配置一种协议类型。

- 执行命令**action { alert | block | allow }**，配置IPS自定义签名的动作。
缺省情况下，IPS自定义签名的动作为alert。

步骤6 配置自定义签名规则。

1. 执行命令**rule name name**，创建自定义签名规则并进入自定义签名规则视图。
缺省情况下，系统未创建自定义签名规则。

说明

为了方便记忆和管理，可以根据实际情况对自定义签名规则进行重新命名。

执行命令**rename new-name**，重新命名自定义签名规则，并进入新的自定义签名规则视图。

2. 执行命令**scope { flow | message | packet }**，配置自定义签名规则的检查范围。
缺省情况下，自定义签名规则检查范围为packet。
3. 执行命令**condition [condition-id] field field-name operate { equal | gthan | lthan | noequal } value value-content**，配置自定义签名规则的检查项。
缺省情况下，自定义签名规则无检查项。
一个自定义签名规则中最多可以配置四个检查项。
4. 配置自定义签名规则的检查顺序。
 - a. 执行命令**check { random-order | sequential }**，配置自定义签名规则的检查顺序。
缺省情况下，自定义签名规则检查顺序为random-order，即随机检查。

说明

选择**sequential**参数后，匹配更严格，有可能导致有些入侵行为没有按从小到大顺序命中
的情况下被当做非入侵行为而被放过。

- b. （可选）选择**sequential**时，执行命令**condition move condition-id to new-condition-id**，移动自定义签名规则的检查项的位置。
5. （可选）执行命令**source-ip { [ipv4] ip-address | any }**，配置自定义签名规则
检查的源IP地址。

缺省情况下，自定义签名规则检查任意源IP地址。

6. （可选）执行命令**source-port** { *start-port end-port* | **any** }，配置自定义签名规则检查的源端口。

缺省情况下，自定义签名规则对所有源端口都检查。

7. （可选）执行命令**destination-ip** { [**ipv4**] *ip-address* | **any** }，配置自定义签名规则检查的目的IP地址。

缺省情况下，自定义签名规则检查任意目的IP地址。

8. （可选）执行命令**destination-port** { *start-port end-port* | **any** }，配置自定义签名规则检查的目的端口。

缺省情况下，自定义签名规则对所有目的端口都检查。

步骤7 （可选）执行命令**quit**，退出自定义签名规则视图。

步骤8 （可选）执行命令**quit**，退出IPS自定义签名视图。

步骤9 （可选）执行命令**ips signature-state** [**signature-id** *signature-id*] { **enabled** | **disabled** }，配置预定义签名的状态。

缺省情况下，系统未配置预定义签名的状态。

步骤10 执行命令**engine configuration commit**，提交配置。

----结束

7.2.8.2 配置 IPS 模板

背景信息

由于加载IPS特征库后，IPS特征库文件动态生成的大量签名是没有进行分类的，且有些签名所包含的特征本网络中不存在，需要通过签名过滤器对签名进行批量过滤并设置统一的动作。并且如果管理员对某些签名专门设定动作时，需要将签名引入到例外签名中。

通过配置IPS模板，可以解决上述问题，并且一个IPS模板下可配置多个签名过滤器和多个例外签名。在IPS模板中配置签名过滤器和例外签名后，可以筛选出适合本网络特征的签名。设备可以通过IPS模板对入侵行为进行入侵防御。

设备缺省存在多个安全配置文件以适用于不同的应用场景，缺省的安全配置文件可以查看、复制或直接被安全策略引用，但是不可以修改或删除。

- **video_surveillance**：包括所有签名，动作采用签名的缺省动作。适用于DNS、HTTP、FTP、TELNET、SSH、RTSP、SSL、UDP、TCP协议。适用于所有威胁类别。该配置文件适用于当设备部署在视频监控的场景。
- **strict**：包括所有签名，动作为阻断。适用于所有协议。适用于所有威胁类别。该配置文件适用于需要设备阻断所有命中签名的报文场景。
- **web_server**：包括所有签名，动作采用签名的缺省动作。适用于DNS、HTTP、FTP协议。适用于所有威胁类别。该配置文件适用于当设备部署在Web服务器前面的场景。
- **file_server**：包括所有签名，动作采用签名的缺省动作。适用于DNS、SMB、NETBIOS、NFS、SUNRPC、MSRPC、FILE、TELNET协议。适用于所有威胁类别。该配置文件适用于当设备部署在File服务器前面的场景。
- **dns_server**：包括所有签名，动作采用签名的缺省动作。适用于DNS协议。适用于所有威胁类别。该配置文件适用于当设备部署在DNS服务器前面的场景。

- **mail_server**: 包括所有签名，动作采用签名的缺省动作。适用于DNS、IMAP4、SMTP、POP3协议。适用于所有威胁类别。该配置文件适用于当设备部署在Mail服务器前面的场景。
- **inside_firewall**: 包括所有签名，动作采用签名的缺省动作。适用于所有协议。适用于所有威胁类别。该配置文件适用于当设备部署在防火墙里面的场景。
- **dmz**: 包括所有签名，动作采用签名的缺省动作。适用于除NETBIOS、NFS、SMB、TELNET和TFTP之外的所有协议。适用于所有威胁类别。该配置文件适用于当设备部署在DMZ区域前的场景。
- **outside_firewall**: 包括所有签名，动作采用签名的缺省动作。适用于所有协议。适用于除Scanner之外的威胁类别。该配置文件适用于当设备部署在防火墙外面的场景。
- **ids**: 包括所有签名，动作为告警。适用于所有协议。适用于所有威胁类别。该配置文件适用于当设备以IDS（旁路）模式部署时的通用场景。
- **default**: 包括所有签名，动作采用签名的缺省动作。适用于所有协议。适用于所有威胁类别。该配置文件适用于当设备以IPS（直路）模式部署时的通用场景。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 创建IPS模板并进入IPS模板视图。

- 创建一个空配置的IPS模板。
执行命令**profile type ips name name**，用来创建IPS模板，并进入IPS模板视图。
- 复制方式创建IPS模板。
执行命令**profile type ips copy old-name [new-name]**，用于通过复制已经存在的IPS模板来创建IPS模板，并进入IPS模板视图。
*old-name*是一个已创建的IPS模板。

缺省情况下，设备上存在IPS模板。名称为：video_surveillance、strict、web_server、file_server、dns_server、mail_server、inside_firewall、dmz、outside_firewall、ids和default。

说明

为了方便记忆和管理，可以根据实际情况对IPS模板进行重新命名。

执行命令**rename new-name**，重新命名IPS模板，并进入新的IPS模板视图。

步骤3 （可选）执行命令**description description**，用来配置IPS模板的描述信息，以辅助标识本IPS模板。

缺省情况下，IPS模板下未配置描述信息。

步骤4 （可选）执行命令**cnc domain-filter enable [action { alert | block }]**，用来开启域名过滤功能。

缺省情况下，域名过滤功能处于关闭状态。

开启域名过滤功能后，缺省的处理动作为告警（alert）。

域名过滤功能通过恶意域名特征库（CNC）对域名进行过滤，保证内网主机不会受到恶意域名的侵害。

说明

- 由于设备本身没有预装CNC库，所以需要用户在获取IPS的License权限后手动从安全中心平台（sec.huawei.com）下载到本地加载或者在线加载CNC库。
- 当设备更换启动路径时，用户需要再次在获取IPS的License权限后手动从安全中心平台（sec.huawei.com）下载到本地加载或者在线加载CNC库。

步骤5 执行命令**signature-set name name**，用来在IPS模板视图下创建一个IPS签名过滤器并进入IPS签名过滤器视图。

缺省情况下，未配置IPS签名过滤器。

一个IPS模板下可配置多个IPS签名过滤器。

说明

为了方便记忆和管理，可以根据实际情况对IPS签名过滤器进行重新命名。

执行命令**rename new-name**，重新命名IPS签名过滤器，并进入新的IPS签名过滤器视图。

步骤6 创建一个IPS签名过滤器后，缺省情况下所有预定义签名都包含在该签名过滤器中。用户根据需要选择执行以下命令，配置签名过滤器的过滤条件来挑选出符合要求的签名。

- 执行命令**category { category-name <1-10> | all }**，用来将指定分类的IPS签名加入IPS签名过滤器中。
缺省情况下，未配置指定分类的IPS签名加入IPS签名过滤器中。
- 执行命令**protocol { protocol-name <1-10> | all }**，用来将指定协议的IPS签名加入IPS签名过滤器中。
缺省情况下，IPS签名过滤器中未指定协议。
- 执行命令**os { android | ios | other | unix-like | windows } ***，用来将指定操作系统的IPS签名加入IPS签名过滤器中。
缺省情况下，IPS签名过滤器中包含全部操作系统的签名。
- 执行命令**severity { high | information | low | medium } ***，用来将指定威胁等级的IPS签名加入IPS签名过滤器中。
缺省情况下，IPS签名过滤器中未指定威胁等级。
- 执行命令**target { both | client | server }**，用来将指定目标的IPS签名加入IPS签名过滤器中。
缺省情况下，IPS签名过滤器中未指定目标。

步骤7 执行命令**action { alert | block | default }**，用来配置IPS签名过滤器的动作。

缺省情况下，签名过滤器的动作为**default**，即签名过滤器使用各签名本身的动作对报文进行处理。

步骤8 执行命令**application { application-name <1-10> | all }**，用来配置签名过滤器中的应用名称。

缺省情况下，系统不对应用名称进行过滤。

应用名称是IPS签名过滤器中的一个过滤条件，可以有针对性的对某些应用进行过滤。
<1-10>表示一条命令一次最多可配置10个应用名称，如果需要配置更多的应用名称，请多次执行本命令，多条命令之间不会相互覆盖。当指定多个应用名称时，报文所属的应用类型只需匹配其中一个，即属于匹配通过。

步骤9 执行命令**quit**，退出签名过滤器视图。

步骤10 （可选）执行命令**signature-set move signature-set-name1 { before | after } signature-set-name2**，用来配置IPS签名过滤器的优先级。

步骤11 （可选）执行命令**exception ips-signature-id ips-signature-id [action { alert | allow | block }]**，用来配置IPS例外签名处理功能。

缺省情况下，IPS例外签名相应方式为放行。

如果IPS例外签名的响应方式与模板、签名集的不同，以IPS例外签名的配置为准。

步骤12 执行命令**quit**，退出IPS模板视图。

步骤13 （可选）执行命令**ips collect-attack-evidence max-session-number session-number [signature-id signature-id]**，用来配置每个CPU上针对单个IPS签名最大攻击取证会话数。

缺省情况下，每个CPU上针对单个IPS签名攻击取证的会话数为5。

管理员可以配置每个CPU上针对单个IPS签名最大可抓取的会话数，在不影响设备性能的前提下，保证可以获取必要的信息用来回溯可能出现的威胁。当设备支持多个CPU时，设备针对单个IPS签名的最大攻击取证会话数等于session-number乘以CPU个数。

步骤14 执行命令**engine configuration commit**，用来对安全策略相关的配置进行提交。

创建或修改安全策略相关配置后，配置内容不会立即生效，需要执行**engine configuration commit**命令来激活配置。因为激活过程所需时间较长，建议您完成所有安全策略相关配置的修改后再统一进行提交。

步骤15 （可选）执行命令**cnc domain-filter exception domain-name domain-name**，用来添加例外域名。

缺省情况下，系统中未配置例外域名。

例外域名必须是恶意域名特征库中已存在的域名，不能添加任意域名为例外域名，添加任意域名是没有意义的。管理员可以根据系统中的威胁日志决定是否将某个恶意域名设置为例外域名，系统不会对例外域名进行域名过滤处理。

步骤16 在入侵防御视图下配置协议异常检测。

配置项	命令
检测HTTP流量中是否存在SSH流量	http ssh-over-http check action { alert block }
检测HTTP报文中是否存在多个Host字段	http multi-host check action { alert block }
检测HTTP报文中的X-Online-Host字段	http x-online-host check { any blacklist multiple } action { alert block } http x-online-host blacklist blacklist
检测HTTP报文中的X-Forwarded-For字段	http x-forwarded-for check { any whitelist } action { alert block } http x-forwarded-for whitelist ipv4 ip-address

配置项	命令
检测DNS报文的协议格式是否异常	dns malformed-packet check action { alert block }
检测DNS报文的查询类型	dns request-type check { <i>start-type</i> [<i>to end-type</i>] action default- action } { alert allow block }

----结束

7.2.8.3 在安全策略下绑定 IPS 模板

背景信息

安全策略是控制设备对流量转发以及对流量进行内容安全一体化检测的策略。启用IPS功能后，需要在安全策略下绑定IPS模板，并在安全域间应用安全策略，设备根据安全策略进行入侵防御。

网络中存在多种业务流量，针对不同的业务流量，设备上也会配置多条安全策略。在安全策略下，可以同时绑定不同类型的模板，但是相同类型的模板只能绑定一个。为了保证安全策略配置的正确性，管理员需要在配置安全策略前，完成安全策略的规划。

说明

如果需要同时配置多种内容安全保护功能（例如，需要同时配置IPS功能和URL过滤功能），请先配置好IPS模板和URL过滤模板，然后通过命令**profile**来在安全策略下绑定。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**security-policy policy-name**，用来创建安全策略，并进入安全策略视图。
缺省情况下，未创建安全策略。
- 步骤3** 执行命令**profile ips ips-name [acl acl-id]**，用来配置安全策略下绑定的IPS模板。
缺省情况下，未在安全策略上绑定IPS模板。
*acl-id*是一个已创建的ACL。
目前，IPS仅支持绑定ACL4，不支持ACL6。

说明

IPS在绑定ACL4时，需要在创建的ACL内配置双向rule规则，才能使配置生效。

----结束

7.2.8.4 在安全域间应用安全策略

前提条件

已创建安全区域并将接口加入了安全区域，具体请参见“防火墙配置”中的[6.6.1 创建安全域并将接口加入安全区域](#)。

背景信息

完成安全策略的配置后，只有指定安全策略应用的范围，才能让安全策略生效。设备认为在同一安全区域内部发生的数据流动是可信的，不需要实施任何安全策略。只有当不同安全区域之间发生数据流动时，才会触发安全检查，并实施相应的安全策略。用户需要配置IPS业务时，需要进入安全域间并在安全域间应用已绑定IPS模板的安全策略。

操作步骤

步骤1 执行命令`system-view`，进入系统视图。

步骤2 执行命令`firewall interzone zone-name1 zone-name2`，创建安全域间并进入安全域间视图。

创建安全域间必须指定两个已存在的安全区域。

安全域间的具体信息，请参见“防火墙配置”中的[6.6.2 创建安全域间](#)。

步骤3 执行命令`security-policy policy-name`，在安全域间应用安全策略。

缺省情况下，安全域间未应用安全策略。

应用安全策略后，如果安全策略下绑定IPS模板时未配置ACL，则设备会对所有安全域间的流量进行IPS检测；如果安全策略下绑定IPS模板时配置了ACL，则设备根据ACL里的rule，来确定是否对流量进行IPS检测。

- 如果ACL的rule配置为permit，设备会对匹配该规则的流量进行检测。
- 如果ACL的rule配置为deny，设备不会对匹配该规则的流量进行检测。
- 如果流量未匹配上ACL，设备也不对流量进行检测。

----结束

7.2.8.5 （可选）控制 IPS 的日志发送功能

背景信息

当某一时刻发生大量入侵行为，导致IPS频繁触发告警和阻断，则IPS会在短时间内向设备上报大量的日志信息。默认情况下，设备会实时输出日志，可能会造成刷屏，干扰管理员正常工作。

为了解决这个问题，可以关闭日志发送功能，也可以配置日志缓存功能，控制IPS的日志发送频率。

日志缓存最大记录1024条日志，每次最多输出16条日志，输出日志从缓存中清空。默认情况下每1分钟定时输出。

说明

当日志缓存记录已满时，超出部分的日志会丢弃。如果配置的定时输出时间过长，导致日志缓存记录已满，可适当调小定时输出时间。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**engine log ips enable**，用来开启指定或所有模块的发送日志功能。
缺省情况下，系统开启所有模块的发送日志功能。
- 步骤3** 执行命令**engine log timeout interval**，配置日志输出频率。
缺省情况下，每1分钟定时输出。
- 步骤4** 执行命令**ips log merge enable**，开启IPS日志汇聚功能。
缺省情况下，开启IPS日志汇聚功能。
- 步骤5** 执行命令**ips log extend enable**，开启IPS日志的扩展信息输出功能。
缺省情况下，未开启IPS日志的扩展信息输出功能。
- 结束

7.2.8.6 检查 IPS 功能配置结果

操作步骤

- 执行命令**display profile type ips [name name [signature-set-name signature-set-name | exception-signature-id exception-signature-id]]**，查看当前IPS模板的配置信息。
 - 执行命令**display ips-signature [pre-defined [associated] | user-defined] [application { application-name | all } | category { category-name | all } | os { all | android | ios | other | unix-like | windows } * | protocol { protocol-name | all } | severity { information | low | medium | high } * | state { disabled | enabled | retired } | target { server | client | both }] ***，查看IPS签名信息。
 - 执行命令**display ips-signature vendor-id vendor-id**，根据厂商ID查看IPS签名信息。
 - 执行命令**display ips signature-id signature-id rule { name rule-name | all }**，查看IPS自定义签名规则内容。
 - 执行命令**display ips signature-state**，查看IPS预定义签名的状态。
 - 执行命令**display ips-signature cve-id { cve-id | year year }**，根据CVE ID查看IPS预定义签名的信息。
 - 执行命令**display ips signature-action**，查看IPS预定义签名动作的配置信息。
 - 执行命令**display cnc domain-filter exception**，查看域名过滤的所有例外域名。
 - 执行命令**display security-policy { name policy-name | all }**，查看安全策略规则。
 - 执行命令**display firewall zone [zone-name] [interface | priority]**，查看安全域的相关信息。
 - 执行命令**display firewall interzone [zone-name1 zone-name2]**，查看安全域间的相关信息。
- 结束

7.2.9 维护 IPS

维护IPS包括查看IPS的统计信息和清除IPS的统计信息。

7.2.9.1 查看 IPS 的统计信息

背景信息

用户需要了解接口下应用指定安全策略后，入侵检测到的告警事件和阻断事件的情况时，可以查看IPS的统计信息。

为了方便用户的查看，用户还可以查看IPS签名命中次数的统计结果，并可以选择查看IPS签名命中次数最多的前100条IPS签名的统计信息。

操作步骤

- 在任意视图下执行**display ips statistics**命令，查看IPS统计信息。
- 在任意视图下执行**display ips-signature statistics topn-number**命令，查看IPS签名命中次数最多的前`topn-number`条IPS签名的统计信息。
- 执行命令**display cnc domain-filter { domain | exception | domain-name domain-name } statistics**，查看域名过滤的统计信息。
- 执行命令**display cnc domain-filter domain statistics topn-number**，查看命中次数最多的前`topn-number`个恶意域名的统计信息。
- 执行命令**display cnc information**，查看CNC库中加载的域名详细信息。

----结束

7.2.9.2 清除 IPS 的统计信息

背景信息

当需要对IPS的统计信息重新进行统计时，可以在用户视图下执行以下命令，清除之前的统计信息。

须知

清除IPS的统计信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

步骤1 执行命令**reset ips statistics**，清除IPS统计信息。

步骤2 执行命令**reset ips-signature statistics { signature-id signature-id | all } { event | collect-attack-evidence | all }**，清除签名的统计信息。

步骤3 执行命令**reset cnc domain-filter { domain | exception | domain-name domain-name } statistics**，清除域名过滤功能的统计信息。

----结束

7.2.10 IPS 配置举例

通过示例介绍如何配置IPS。配置示例中包括组网需求、配置注意事项、配置思路等。

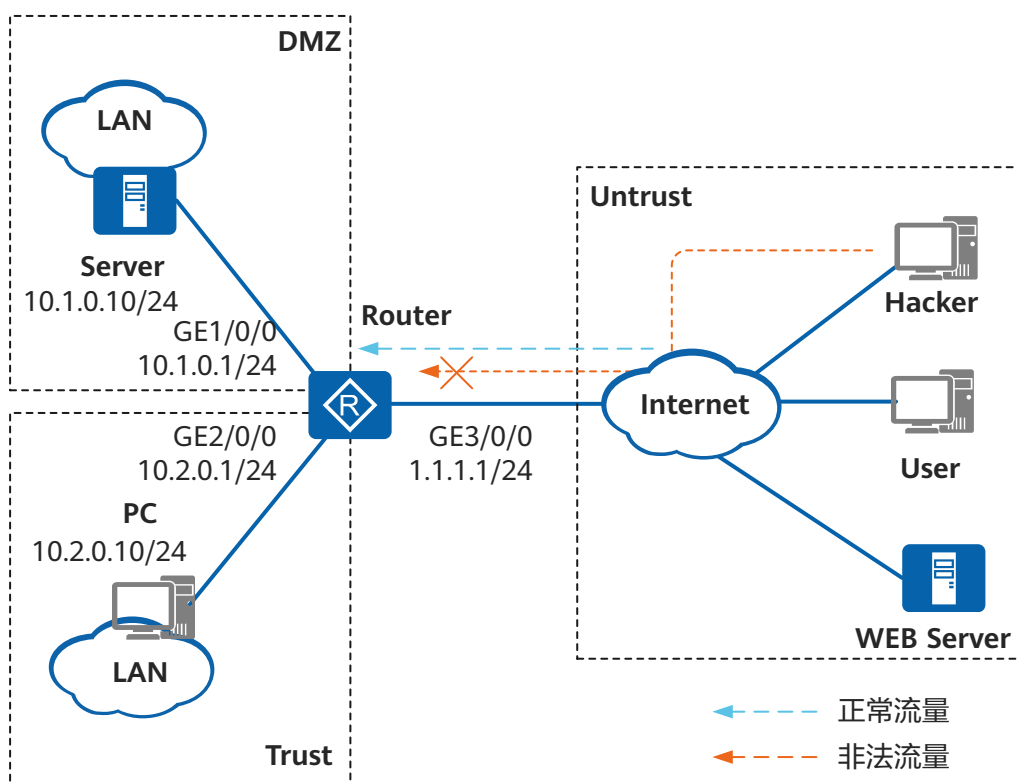
7.2.10.1 配置 IPS 阻断入侵行为示例

组网需求

如图7-9所示，企业部署了Router作为安全网关。其中，企业员工所在内网用户部署在Trust区域，内网服务器部署在DMZ区域。

为了防止内网用户和内网服务器受到蠕虫、木马、僵尸网络等入侵行为的攻击，需要对不同区域之间的流量进行安全检测，并及时阻断入侵行为，保护公司内部网络安全。

图 7-9 配置 IPS 阻断入侵行为组网图



配置思路

采用如下的思路配置IPS阻断入侵行为：

1. 配置相关接口的IP地址和路由，保证路由互通。
2. 将内网服务器、内网用户和外部网络划分在三个安全区域DMZ、Trust和Untrust中，实现对不同安全区域之间的网络流量的监控。
3. 针对内网用户，配置IPS模板profile_ips_pc。

- a. 检测并防御威胁等级为“高”的入侵行为。
 - b. 检测并防御协议类型为HTTP、FTP的入侵行为。
 - c. 检测并防御目标是客户端的入侵行为。
4. 针对内网服务器，配置IPS模板profile_ips_server。
 - a. 检测并防御威胁等级为“高”的入侵行为。
 - b. 检测并防御协议类型为FTP的入侵行为。
 - c. 检测并防御目标是服务器的入侵行为。
 - d. 对攻击出现次数较多的入侵行为通过例外签名进行阻断。
5. 配置需要进行内容安全检测的对象。
6. 配置两个安全策略policy_sec_1和policy_sec_2，分别绑定IPS模板profile_ips_pc和profile_ips_server，以对网络流量进行对应的内容安全检测。
7. 在Trust到Untrust域间应用安全策略policy_sec_1，使安全策略生效，保护内网用户免受来自Internet的攻击。
8. 在Untrust到DMZ域间以及Trust到DMZ域间应用安全策略policy_sec_2，使安全策略生效，保护内网服务器免受来自内网用户和Internet的攻击。

操作步骤

步骤1 在Router上配置安全区域和安全域间。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] engine enable
[Router] firewall zone DMZ
[Router-zone-DMZ] priority 14
[Router-zone-DMZ] quit
[Router] firewall zone Trust
[Router-zone-Trust] priority 13
[Router-zone-Trust] quit
[Router] firewall zone Untrust
[Router-zone-Untrust] priority 1
[Router-zone-Untrust] quit
[Router] firewall interzone Trust Untrust
[Router-interzone-Trust-Untrust] quit
[Router] firewall interzone DMZ Trust
[Router-interzone-DMZ-Trust] quit
[Router] firewall interzone DMZ Untrust
[Router-interzone-DMZ-Untrust] quit
```

步骤2 在Router上配置接口IP地址，并将接口加入安全区域。

```
[Router] interface gigabitethernet 1/0/0
[Router-GigabitEthernet1/0/0] ip address 10.1.0.1 24
[Router-GigabitEthernet1/0/0] zone DMZ
[Router-GigabitEthernet1/0/0] quit
[Router] interface gigabitethernet 2/0/0
[Router-GigabitEthernet2/0/0] ip address 10.2.0.1 24
[Router-GigabitEthernet2/0/0] zone Trust
[Router-GigabitEthernet2/0/0] quit
[Router] interface gigabitethernet 3/0/0
[Router-GigabitEthernet3/0/0] ip address 1.1.1.1 24
[Router-GigabitEthernet3/0/0] zone Untrust
[Router-GigabitEthernet3/0/0] quit
```

步骤3 配置IPS模板profile_ips_pc，保护内网用户。通过配置签名过滤器来满足安全需要。

```
[Router] profile type ips name profile_ips_pc
[Router-profile-ips-profile_ips_pc] signature-set name filter1
[Router-profile-ips-profile_ips_pc-sigset-filter1] target client
[Router-profile-ips-profile_ips_pc-sigset-filter1] severity high
[Router-profile-ips-profile_ips_pc-sigset-filter1] protocol HTTP FTP
```

```
[Router-profile-ips-profile_ips_pc-sigset-filter1] action default
[Router-profile-ips-profile_ips_pc-sigset-filter1] quit
[Router-profile-ips-profile_ips_pc] quit
```

- 步骤4** 配置IPS模板profile_ips_server，保护内部网络服务器。另外，通过观察日志发现有一种攻击出现次数较多，其匹配的签名ID为74320，需将这种攻击全部阻断。

```
[Router] profile type ips name profile_ips_server
[Router-profile-ips-profile_ips_server] signature-set name filter1
[Router-profile-ips-profile_ips_server-sigset-filter1] target server
[Router-profile-ips-profile_ips_server-sigset-filter1] severity high
[Router-profile-ips-profile_ips_server-sigset-filter1] protocol FTP
[Router-profile-ips-profile_ips_server-sigset-filter1] action default
[Router-profile-ips-profile_ips_server-sigset-filter1] quit
[Router-profile-ips-profile_ips_server] exception ips-signature-id 74320 action block
[Router-profile-ips-profile_ips_server] quit
[Router] engine configuration commit
```

- 步骤5** 创建安全策略policy_sec_1，并引用IPS模板profile_ips_pc。

```
[Router] security-policy policy_sec_1
[Router-security-policy-policy_sec_1] profile ips profile_ips_pc
[Router-security-policy-policy_sec_1] quit
```

- 步骤6** 创建安全策略policy_sec_2，并引用IPS模板profile_ips_server。

```
[Router] security-policy policy_sec_2
[Router-security-policy-policy_sec_2] profile ips profile_ips_server
[Router-security-policy-policy_sec_2] quit
```

- 步骤7** 在Trust到Untrust域间应用安全策略policy_sec_1，使安全策略生效，保护内网用户免受来自Internet的攻击。

```
[Router] firewall interzone Trust Untrust
[Router-interzone-Trust-Untrust] security-policy policy_sec_1
[Router-interzone-Trust-Untrust] quit
```

- 步骤8** 在DMZ到Untrust域间以及DMZ到Trust域间应用安全策略policy_sec_2，使安全策略生效，保护内网服务器免受来自内网用户和Internet的攻击。

```
[Router] firewall interzone DMZ Untrust
[Router-interzone-DMZ-Untrust] security-policy policy_sec_2
[Router-interzone-DMZ-Untrust] quit
[Router] firewall interzone DMZ Trust
[Router-interzone-DMZ-Trust] security-policy policy_sec_2
[Router-interzone-DMZ-Trust] quit
```

- 步骤9** 验证配置结果。

在Router上执行命令**display security-policy name policy-name**，可以观察到该安全策略规则。

```
<Huawei> display security-policy name policy_sec_1
Policy-name: policy_sec_1
Policy-ID: 4
IPS: profile_ips_pc
URLF: -
ACL: 0
Reference-Num: 1
```

在Router上执行**display firewall interzone zone-name1 zone-name2**，结果如下。

```
<Huawei> display firewall interzone Trust Untrust
interzone Trust Untrust
firewall disable
security-policy policy_sec_1
packet-filter default deny inbound
packet-filter default permit outbound
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
engine enable
#
profile type ips name profile_ips_pc
signature-set name filter1
target client
severity high
protocol HTTP FTP
#
profile type ips name profile_ips_server
signature-set name filter1
target server
severity high
protocol FTP
exception ips-signature-id 74320 action block
#
security-policy policy_sec_1
profile ips profile_ips_pc
security-policy policy_sec_2
profile ips profile_ips_server
#
firewall zone Untrust
priority 1
#
firewall zone DMZ
priority 14
#
firewall zone Trust
priority 13
#
firewall interzone Trust Untrust
security-policy policy_sec_1
#
firewall interzone DMZ Trust
security-policy policy_sec_2
#
firewall interzone DMZ Untrust
security-policy policy_sec_2
#
interface GigabitEthernet1/0/0
ip address 10.1.0.1 255.255.255.0
zone DMZ
#
interface GigabitEthernet2/0/0
ip address 10.2.0.1 255.255.255.0
zone Trust
#
interface GigabitEthernet3/0/0
ip address 1.1.1.1 255.255.255.0
zone Untrust
#
return
```

7.3 URL 过滤配置

通过配置URL过滤，可以对用户访问的URL进行控制，允许或禁止用户访问某些网页，以达到规范上网行为的目的。

7.3.1 URL 过滤简介

介绍URL过滤的定义和目的。

随着互联网应用的迅速发展，计算机网络在经济和生活的各个领域迅速普及，使得信息的获取、共享和传播更加方便，但同时也给企业带来了前所未有的威胁：

- 员工在工作时间随意访问与工作无关的网站，严重影响了工作效率。
- 员工随意访问非法或恶意的网站，可能会带来病毒、木马、蠕虫等威胁攻击。
- 在内部网络拥堵时段，无法保证员工正常访问与工作相关的网站（如公司主页、搜索引擎等），影响工作效率。

URL过滤功能可以解决上述问题，URL过滤功能可以对用户访问的URL进行控制，允许或禁止用户访问某些网页资源，达到规范上网行为的目的。URL过滤还可以通过引用时间段或用户/组等配置项，实现针对不同时间段或不同用户/组的URL访问控制，达到更加精细化和准确化控制员工上网权限的需求。

7.3.2 URL 过滤原理描述

通过URL过滤策略，精确管理用户使用HTTP访问网络资源的请求。

7.3.2.1 URL 匹配方式

设备接收到用户发送的HTTP请求报文后，对HTTP报文进行解析，通过不同的URL匹配方式进行匹配。如果成功匹配，设备根据匹配后的动作对用户的请求进行处理。

Internet上的每一个网页及其资源都具有一个唯一的标识，称为URL地址（简称URL）。

URL地址一般格式为“protocol://hostname[:port]/path[?query]”。各字段含义如表7-7所示。

表 7-7 URL 地址中各字段的解释

字段	含义
protocol	使用的应用层协议，最常用的是HTTP协议。
hostname	Web服务器的域名或者IP地址。
:port	通信端口，可选。各种应用层协议都有默认的端口号，如HTTP协议的默认端口为80。当服务器采用默认端口时，URL过滤规则中不用配置端口号。当服务器采用非默认端口时，URL过滤规则中不能省略端口号。
path	由零个或多个“/”符号隔开的字符串，一般用来表示Web服务器上的一个目录或文件地址。
?query	用于给动态网页传递参数，可选。

URL匹配方式包括前缀匹配、后缀匹配、关键字匹配、精确匹配四种。如表7-8所示，设备可以通过这四种URL匹配方式来定义希望匹配的URL的范围。

表 7-8 多样化的 URL 匹配方式

匹配方式	定义	举例	匹配结果
前缀匹配	匹配所有以指定字符串开头的 URL。	test.com*	匹配所有以 test.com开头的 URL，如： - test.com - test.com.cn - test.com/solutions.do 以下URL不会匹配： www.test.com
后缀匹配	匹配所有以指定字符串结尾的 URL。	*test.com	匹配所有以 test.com结尾的 URL，如： - www.test.com - newtest.com 以下URL不会匹配： - www.test.com.cn - www.test.com/news
关键字匹配	匹配所有包含指定字符串的 URL。	*test*	匹配所有包含test的URL，如： - sports.test.com/news/solutions.aspx - newtest1.com/it/

匹配方式	定义	举例	匹配结果
精确匹配	首先判断URL和指定字符串是否匹配，如果未匹配，则去除URL的最后一个目录，再和指定字符串进行匹配；如果还未匹配，则继续去除URL的最后一个目录，再和指定字符串进行匹配。以此类推，直到用域名去匹配指定的字符串为止。	www.example.com	根据匹配规则，以下URL可以匹配 www.example.com。 - www.example.com - www.example.com/news - www.example.com/news/en/ 以下URL不会匹配该条目： - www.example.com.cn/news - www.example.org/news/

URL进行匹配时，不同的匹配方式存在如下优先级顺序，由高至低如下所示：

精确匹配 > 后缀匹配 > 前缀匹配 > 关键字匹配

例如，URL“www.example.com/news”同时符合以下条目，则查询结果以精确匹配条件“www.example.com/news”对应的URL分类为准。

- 精确匹配：www.example.com/news
- 前缀匹配：www.example.com/*
- 关键字匹配：*example*

在同一种匹配方式下，匹配规则越长优先级越高。例如以下条目均属于前缀匹配方式，则URL“www.example.com/news/index.html”会优先匹配“www.example.com/news/*”条目。

- www.example.com/news/*
- www.example.com/*

在同一种匹配方式下，如果匹配规则长度也相同，则最终以配置的动作模式为准。如表7-9所示，两个条目均属于“关键字匹配”方式，且匹配规则长度相同均为4。对于URL“www.example.com/welcome.html”来说：

- 当动作模式为“严格模式”时，则最终查询结果以动作最为严格的URL分类为准，本例中为URL分类B，动作为阻断。
- 当动作模式为“松散模式”时，则最终查询结果以动作最为宽松的URL分类为准，本例中为URL分类A，动作为允许。

表 7-9 动作模式

条目	URL分类	控制动作
.com	URL分类A	允许
html	URL分类B	阻断

 说明

- 对于所有匹配方式，设备会去除输入字符串中包含的前缀“http://”，如果是精确匹配，对于hostname字段后没有“/”的字符串会在末尾增加“/”。
- URL条目不区分大小写。
- 本节主要介绍URL匹配的相关细节，更多关于URL控制动作的内容请参考[URL过滤实现原理](#)。

7.3.2.2 URL 过滤实现原理

当用户的URL访问请求通过不同的匹配方式匹配到某条URL之后，设备会根据配置的[URL过滤方式](#)，采用[URL过滤处理流程](#)对此URL访问请求作出相应的处理。

URL 过滤方式

设备支持基于黑白名单和基于分类的URL过滤。

 说明

AR300系列设备不支持URL远程查询功能，当前实现采用内置本地库且不支持远端动态更新，本地库维护了部分主流WEB网站，被称为预定义分类，用来对一些常见的网站进行访问控制。随着网络的发展，对于新出现的网站，预定义URL分类可能覆盖不到。如果用户查询到URL分类，则按照URL过滤配置文件中配置的响应动作进行处理。如果查询不到，则按照缺省动作处理请求。如果用户想继续过滤URL分类，可以通过配置URL黑名单或URL白名单，实现过滤网站的目的。

- 基于黑白名单的URL过滤：用户通过在设备上手动配置[URL白名单](#)或[URL黑名单](#)，对收到的HTTP请求报文进行过滤。
- 基于分类的URL过滤：设备收到HTTP请求报文后，在[URL分类](#)中查询该URL的分类。当查询到该URL的分类后，设备根据预先配置的URL分类的[响应动作](#)，对HTTP请求执行相应的动作。

URL黑白名单、URL分类和响应动作的说明如下：

- **URL白名单**：企业可以将日常允许访问的网络资源的URL加入到URL白名单中。当用户发送的HTTP请求中的URL在白名单中时，设备直接允许该报文通过。
- **URL黑名单**：企业可以将日常禁止访问的网络资源的URL添加到URL黑名单中。当用户发送的HTTP请求中的URL在黑名单中时，设备直接禁止该报文通过，同时向用户返回黑名单阻断页面。
- **URL分类**：分为自定义分类和预定义分类。
 - 自定义分类：由管理员手工配置和维护。相对于预定义分类，管理员可以使用自定义分类对URL进行更为精细化的控制。
 - 预定义分类：系统已经预先对大量常见的URL进行了分类。相对于需要手工配置的自定义分类，管理员可以根据系统预置的这些分类轻松地控制企业用户禁止或允许访问哪些类别的URL。

设备URL预定义分类查询方式为：

- URL本地过滤：设备出厂时会预置一个URL预分类库并加载至本地缓存中，一般情况下，用户采用该库即可。但当预置的URL预分类库自动加载失败或安全服务中心已更新URL预分类库时，用户可以手动将新的URL预分类库加载至本地缓存中。当设备提取了URL信息后，首先会在缓存中查询该URL对应的分类。如果查询到URL分类，则按照URL过滤配置文件中配置的响应动作进行处理。如果查询不到，则按照缺省动作处理请求。
- **响应动作：**在查询到URL的分类后，设备根据配置的动作做出响应。目前，设备支持配置允许（allow）、告警（alert）和阻断（block）三种响应动作。
 - 允许（allow）：设备对该HTTP报文不进行处理，允许其通过。
 - 告警（alert）：设备允许HTTP报文通过，但会记录日志。
 - 阻断（block）：设备禁止HTTP报文通过，同时记录日志。同时设备会向发起HTTP请求的用户返回阻断页面。

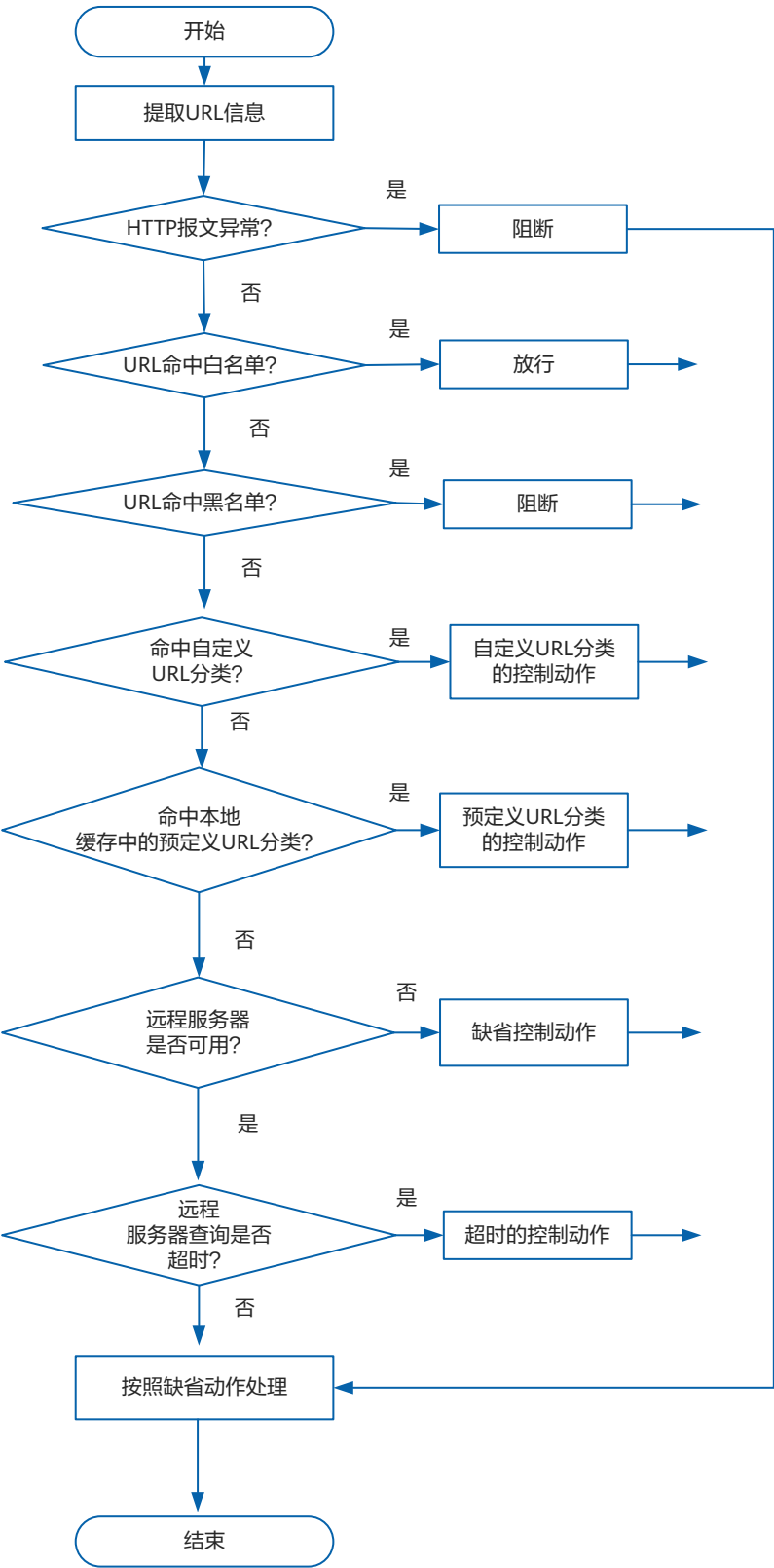
当URL属于多个分类时，响应动作将按照动作模式执行：

- 严格模式：最终动作取所有命中分类中最严格的动作。例如URL属于2个分类，响应动作分别为“告警”和“阻断”，此时执行“阻断”。
- 松散模式：最终动作取所有命中分类中最宽松的动作。例如URL属于2个分类，响应动作分别为“告警”和“阻断”，此时执行“告警”。

URL 过滤处理流程

在设备启用URL过滤功能的情况下，当用户访问某个网络资源的HTTP请求通过设备时，设备将进行URL过滤。处理流程如图1所示。

图 7-10 URL 过滤处理流程图



设备检测出该请求中的URL并通过URL匹配方式匹配到某条URL后，开始URL查询过程：

1. 用户发起URL访问请求，如果数据流匹配了安全策略，且安全策略的动作为允许，则进行URL过滤处理流程。
2. 检测HTTP报文是否异常。
 - 如果HTTP报文异常，则阻断该请求。
 - 如果HTTP报文正常，则进行下一步检测。
3. 将URL信息与白名单进行匹配。
 - 如果匹配白名单，则允许该请求通过。
 - 如果未匹配白名单，则进行下一步检测。
4. 将URL信息与黑名单进行匹配。
 - 如果匹配黑名单，则阻断该请求。
 - 如果未匹配黑名单，则进行下一步检测。
5. 将URL信息与自定义分类进行匹配。
 - 如果匹配自定义分类，则按照自定义URL分类的控制动作处理请求。

说明

管理员自行向预定义分类中添加的URL属于自定义分类的URL。

- 如果未匹配自定义分类，则进行下一步检测。
6. 将URL信息与本地缓存中的预定义分类进行匹配。
 - 如果在本地缓存中查询到对应的分类，则按照该分类的控制动作处理请求。
 - 如果在本地缓存中没有查询到对应的分类，则按照缺省动作处理请求。
 7. 启动远程查询。
 - 如果远程查询服务器在设定的超时时间内没有返回结果，则按照管理员配置的“超时后动作”处理。
 - 如果远程查询服务器上明确查询到该URL属于某个预定义分类，则按照该分类的控制动作处理。

说明

如果该URL不属于任何一个确定的分类，则按照“其他”类的控制动作处理该请求。

说明

当一条会话中含有多个URL时，设备会对每个URL分别进行过滤处理，只要其中任一URL被阻断，则整个会话将会被阻断。

7.3.2.3 URL 远程查询过程

当设备支持URL远程查询功能时，可以通过远程查询扩充本地的预定义URL分类库，便于下一次的快速查询。

一般来说，URL远程查询由调度中心、调度服务器和查询服务器共同完成。各设备的作用如下：

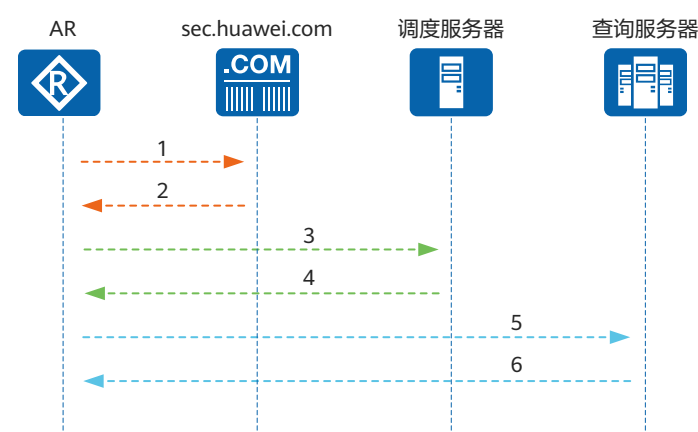
- 调度中心：调度中心的域名为sec.huawei.com，作用是对设备进行设备认证。如果认证通过，调度中心将根据设备所在的国家/地区信息，向设备提供该区域内的调度服务器地址和端口。
和调度中心进行交互时，协议为TCP，目的端口为80。

- 调度服务器：调度服务器的作用是向设备提供区域内的查询服务器地址和端口。由于调度服务器是分区域部署的，所以设备上必须配置正确的国家/地区信息，否则无法成功获取到调度服务器的地址和端口。
和调度服务器进行交互时，协议为TCP，目的端口为12612。
- 查询服务器：查询服务器的作用是处理查询请求，并将查询结果返回给设备。查询服务器也是分区域部署的，且和调度服务器存在配套关系，即调度服务器只能向设备提供同一区域内的查询服务器地址和端口。
和查询服务器进行交互时，协议为UDP，目的端口为12600。

远程模式下，设备与调度中心进行通信。调度服务器根据设备上配置的国家/地区信息，转发查询请求给该国家/地区内的查询服务器处理。

远程模式下的大致交互过程如图1所示。

图 7-11 URL 远程查询过程



1. 设备向调度中心发起认证请求，并请求调度服务器的地址。
2. 认证通过后，调度中心根据设备的国家/地区信息，向设备提供该区域内的调度服务器地址和端口。
3. 设备向调度服务器请求查询服务器的地址和端口。
4. 调度服务器确认设备的设备信息无误后，向设备提供查询服务器的地址和端口。一般来说，设备将收到多个查询服务器的地址和端口。
5. 设备向所有查询服务器发起测速消息，并根据响应速度从中选出最优服务器，然后向该服务器请求URL分类信息。
6. 查询服务器反馈URL分类信息，设备将根据此分类信息继续进行URL过滤。

7.3.3 URL 过滤应用场景

介绍URL过滤的应用场景。

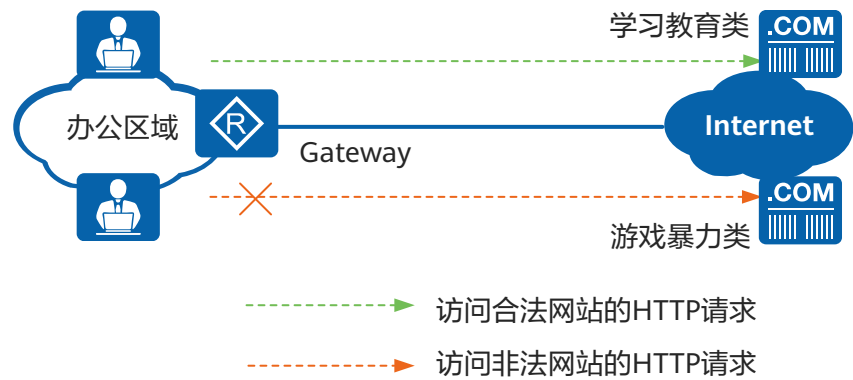
7.3.3.1 使用 URL 过滤规范上网行为

URL过滤功能通常用于企业网关，精确管理用户使用HTTP/HTTPS访问网络资源的行为。

如图7-12所示，设备作为企业网关部署在网络边界，当企业用户发起HTTP/HTTPS请求时，通过URL过滤功能可以允许或禁止用户访问某些网站资源。例如：

- 当用户访问学习教育类的网站时，设备允许其访问。
- 当用户访问游戏暴力类的网站时，设备禁止其访问。

图 7-12 URL 过滤的典型应用场景



7.3.4 URL 过滤配置注意事项

涉及网元

无需其他网元配合。

License 支持

表 7-10 URL 过滤支持的 License 列表

系列	License支持情况
AR300&AR700系列	AR300系列&AR700系列无需获得License许可即可应用该功能。

硬件依赖

表 7-11 URL 硬件依赖

系列	特性支持情况
AR300&AR700系列	仅AR720和AR730支持URL远程查询功能。

特性依赖和限制

在路由器上部署URL过滤特性时，需要注意：

- 设备支持URL过滤功能，这些功能涉及采集或存储个人用户通信内容。本公司无法单方采集或存储用户通信内容。建议您只有在所适用法律法规允许的目的和范围内方可启用相应的功能。在使用、存储用户通信内容的过程中，您应采取足够的措施以确保用户的通信内容受到严格保护。
- URL过滤功能只支持过滤HTTP或HTTPS协议的URL请求。当需要过滤HTTPS协议的URL请求时，还需要配置加密流量过滤功能。加密流量过滤功能实现的URL过滤是基于域名级别，不够精确，即通过从客户端Client Hello报文的SNI（Server Name Indication）字段、服务器Certificate报文的CN（Common Name）和SAN（Subject Alternative Name）字段中获取用户访问的网站域名。如果用户使用加密流量过滤功能实现HTTPS URL过滤，请先阅读以下使用限制：
 - 在浏览器存在代理的情况下，当用户访问某些网站时，路由器从客户端Client Hello报文的SNI字段、服务器Certificate报文的CN和SAN字段中提取的网站域名可能与实际网站的域名不匹配，这会导致URL过滤功能不生效。例如当用户通过手机的UC浏览器访问优酷网站时，URL过滤功能不生效，通过关闭手机UC浏览器的云加速功能可以解决。
 - 当某些浏览器传输数据采用私有协议时，可能导致URL过滤功能不生效。例如谷歌浏览器默认使用私有协议QUIC（Quick UDP Internet Connection）进行数据传输，该协议使用专门的加密方式，路由器不能解密，导致URL过滤无法过滤通过谷歌浏览器访问的HTTPS网站。
 - 当某些网站服务器通过相同的IP地址为多个域名提供服务时，SNI字段可能会包含多个域名，如果URL过滤黑名单只配置了其中一个域名，则无法阻断所有来自这个网站的流量。例如，用户通过HTTPS访问网站www.example.com，该网站可能有多个域名，例如1.example.com、2.example.com等，如果仅在URL过滤黑名单中配置1.example.com，则不能完全阻断这个网站的流量，通过在黑名单中配置一级域名*.example.com可以解决。
 - 当一个证书中有多个URL（即多个网站使用一个证书）时，SAN字段可能会包含多个URL，如果其中一个URL被阻断，会导致这条流量都被阻断，其他的URL也访问不了。
 - 如果将某个网站的域名加入URL过滤白名单，则不能保证该网站下的所有内嵌网页都正常访问。例如：当访问网站www.example.com时，如果只配置白名单为www.example.com，则该网站下不是以www.example.com为域名的内嵌网页均不能正常访问。
 - 由于加密流量过滤功能是通过SSL握手报文实现URL过滤的，客户端尚未发起HTTP请求，因此不支持发送URL推送信息。
- URL过滤功能可以对所有URL请求进行过滤，包括用户要访问的网页及该网页内嵌的所有网站链接。一般来说，URL过滤规则针对的是网页自身的URL地址，如需对网页内嵌的网站链接进行管控，请单独配置URL过滤规则。
- URL规则中如果包含字符“#”，则“#”及“#”后面的字符串在匹配时不会生效；用户访问的URL地址中如果包含字符“#”，则“#”及“#”后面的字符串不会送入URL模块进行匹配处理。
- 当一条会话中含有多个URL时，设备会对每个URL分别进行过滤处理，只要其中任一URL被阻断，则整个会话将会被阻断。
- 部署在两台路由设备中间，且两台路由设备通过BFD互相探测时，建议将路由设备上的BFD检测时间适当调大（建议大于100ms），避免网络偶发性拥塞时导致BFD震荡。
- HTTPS协议的URL过滤需要配置模糊匹配方法，才能确保URL黑白名单等功能生效。例如www.huawei.com的模糊匹配方式可以配置为*huawei*。

- HTTP协议的默认端口为80、HTTPS协议的默认端口号为443。当服务器采用默认端口时，URL过滤规则中不用配置端口号。当服务器采用非默认端口时，URL过滤规则中不能省略端口号。例如，阻断10.1.1.1的访问，如果服务器使用默认端口80，在URL过滤黑名单中配置为10.1.1.1，就能阻断该访问，不用配置为10.1.1.1: 80；如果服务器端口为8080，在URL过滤黑名单中要配置为10.1.1.1: 8080，才能阻断该访问。
- URL过滤的加密流量过滤功能仅能处理TLS 1.0及1.0以上版本协议。
- 在报文来回路径不一致的组网环境中，URL过滤功能不可用。
- URL过滤特性仅支持IPv4。
- 如果浏览器（例如谷歌浏览器）缓存过主页面，当再次访问该页面时，浏览器不会请求主页面，只会刷新主页面上的子页面，这可能会导致URL过滤推送页面无法正常显示，建议在使用URL过滤推送页面功能之前清理浏览器的缓存。
- HTTPS页面被阻断时，可能会导致URL过滤推送页面无法正常显示。

7.3.5 开启深度安全防御功能

背景信息

如果需要使用IPS功能、URL过滤或者AV反病毒功能，除购买对应License外，同时还需要通过执行**engine enable**命令开启深度安全防御功能。

开启深度安全功能后，如果需要关闭该功能，请执行命令**undo engine enable**并重启设备，关闭深度安全功能才生效。重启后，有关深度安全的配置将不存在。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**engine enable**，开启深度安全防御功能。

缺省情况下，系统未开启深度安全防御功能。

----结束

7.3.6 配置 URL 过滤

介绍URL过滤详细的配置过程。

7.3.6.1 配置 URL 过滤模板

背景信息

为了实现精确管理用户上网行为的目的，URL过滤模板支持通过预定义、自定义和黑白名单三种过滤方式，允许或禁止用户访问某个或某类URL。当设备识别出用户的报文为HTTP请求报文后，设备会进行进一步的内容过滤，提取出其中的URL字段并将其与配置的黑白名单、自定义或预定义进行匹配，如果匹配上，则根据配置的响应动作对其进行处理。

三种方式的应用场景如下：

- 对于企业员工访问的大部分常见的网站，通过URL预定义分类即可方便的控制。

- 对于某些新出现的预定义分类尚未覆盖到的网站或是管理员由于特殊需求定制的网站，可以通过配置URL自定义分类来满足需求。
- 对于任何时候都禁止企业员工访问的网站，可以将这些网站加入到黑名单中。
- 对于任何时候允许企业员工访问的网站，可以将这些网站加入到白名单中。

一般情况下，预定义方式为必选配置，自定义和黑白名单方式为预定义方式的有效补充，请根据实际情况选择配置。

在预定义分类方式、自定义分类方式和黑白名单方式中，如果添加重复的规则，那么多条相同的规则记做1条规则。

操作步骤

- 配置URL过滤模板（预定义分类方式）

- a. （可选）配置URL预定义分类。

本地URL分类缓存查询：

- i. 执行命令**system-view**，进入系统视图。
- ii. 执行命令**url-filter category pre-defined subcategory-id subcategory-id**，进入URL预定义分类的小类视图。

说明

设备出厂时会预置一个URL预分类库，一般情况下，用户采用该库即可。但当预置的URL预分类库自动加载失败或安全服务中心已更新URL预分类库时，需要通过执行命令**import url-sdb file filename**，导入新的URL预分类库。

- iii. 执行命令**add { url url-text | host host-text }**，向预定义分类中添加URL规则或域名规则。

缺省情况下，未向预定义分类中添加URL规则或域名规则。

- iv. 执行命令**quit**，返回系统视图。

- b. 配置URL预定义分类的响应动作。

- i. 执行下面命令选择其中一种方式来创建URL过滤模板并进入URL过滤模板视图。

- 如果设备上不存在URL过滤模板，需要执行命令**profile type url-filter name name**，创建URL过滤模板，并进入URL过滤模板视图。
- 如果设备上已经存在URL过滤模板，为了提高配置效率，可以执行命令**profile type url-filter copy old-name [new-name]**，通过复制已经存在的URL过滤模板来创建新的URL过滤模板，并进入新URL过滤模板视图。

缺省情况下，未创建URL过滤模板。

- ii. （可选）执行命令**category action mode { strict | loose }**，配置URL分类的动作模式。

缺省情况下，URL分类的动作模式为严格模式。

- iii. （可选）执行命令**description description**，配置URL过滤模板的描述信息。

缺省情况下，未配置URL过滤模板的描述信息。

- iv. 执行命令**category pre-defined control-level { high | low | medium }**，配置URL预定义分类的控制动作级别。

缺省情况下，URL预定义分类的控制动作级别为低。

系统定义了高、中、低三个级别并根据每个级别对所有预定义分类都设置了一个初始的处理动作。其中，高级别代表相对比较严格的分类处理动作（例如：高级别对色情、P2P下载、视频等分类都进行了阻断），低级别代表相对比较宽松的分类处理动作（例如：低级别对色情类、暴力、钓鱼、恶意网站等URL进行了阻断）。高级别的分类处理动作会包含中级别和低级别的分类处理动作。

- v. 执行命令**category pre-defined** [**category-id** *category-id* | **subcategory-id** *subcategory-id*] **action** { **allow** | **block** | **alert** }，配置URL预定义分类的动作。

缺省情况下，URL预定义分类的动作为允许。

- vi. （可选）执行命令**default action** { **allow** | **block** | **alert** }，配置URL过滤模板的默认动作。

缺省情况下，URL预定义分类的默认动作为允许。

- vii. （可选）执行命令**https-filter enable**，开启加密流量过滤功能。

缺省情况下，关闭加密流量过滤功能。

- viii. 执行命令**quit**，返回系统视图。

- ix. 执行命令**engine configuration commit**，对URL过滤相关的配置进行提交。

创建或修改安全策略相关配置（包括入侵防御和URL过滤的配置）后，配置内容不会立即生效，需要执行**engine configuration commit**命令来激活配置。因为激活过程所需时间较长，建议您完成所有安全策略相关配置的修改后再统一进行提交。

- 配置URL过滤模板（自定义分类方式）

- a. 配置URL自定义分类。

- i. 执行命令**system-view**，进入系统视图。
 - ii. 执行下面命令选择其中一种方式来创建URL自定义分类并进入URL自定义分类视图。

- 执行命令**url-filter category user-defined name** *category-name*，创建URL自定义分类，并进入URL自定义分类视图。
 - 如果新建的URL自定义分类内容和已存在的URL预定义分类内容较相似，可以执行命令**url-filter category pre-defined copy** *subcategory-id new-name*，通过复制URL预定义分类来创建新的URL自定义分类，并进入新URL自定义分类视图。
 - 如果新建的URL自定义分类和已存在的URL自定义分类内容较相似，可以执行命令**url-filter category user-defined copy** *old-name [new-name]*，通过复制已经存在的URL自定义分类来创建新的URL自定义分类，并进入新URL自定义分类视图。

缺省情况下，未创建URL自定义分类。

- iii. （可选）执行命令**description** *description*，配置URL自定义分类的描述信息。

缺省情况下，未配置URL自定义分类的描述信息。

- iv. 执行命令**add** { **url** *url-text* | **host** *host-text* }，向自定义分类中添加URL规则或域名规则。

缺省情况下，未向自定义分类中添加URL规则或域名规则。

- v. 执行命令**quit**，返回系统视图。
- b. 指定URL自定义分类的响应动作。
 - i. 执行下面命令选择其中一种方式来创建URL过滤模板并进入URL过滤模板视图。
 - 如果设备上不存在URL过滤模板，需要执行命令**profile type url-filter name name**，创建URL过滤模板，并进入URL过滤模板视图。
 - 如果设备上已经存在URL过滤模板，为了提高配置效率，可以执行命令**profile type url-filter copy old-name [new-name]**，通过复制已经存在的URL过滤模板来创建新的URL过滤模板，并进入新URL过滤模板视图。

缺省情况下，未创建URL过滤模板。
 - ii. （可选）执行命令**description description**，配置URL过滤模板的描述信息。

缺省情况下，未配置URL过滤模板的描述信息。
 - iii. 执行命令**category user-defined [name category-name] action { allow | block | alert }**，配置URL自定义分类的动作。

缺省情况下，URL自定义分类的动作为允许。
 - iv. （可选）执行命令**https-filter enable**，开启加密流量过滤功能。

缺省情况下，关闭加密流量过滤功能。
 - v. 执行命令**quit**，返回系统视图。
 - vi. 执行命令**engine configuration commit**，对URL过滤相关的配置进行提交。
- 配置URL过滤模板（黑白名单方式）
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行下面命令选择其中一种方式来创建URL过滤模板并进入URL过滤模板视图。
 - 如果设备上不存在URL过滤模板，需要执行命令**profile type url-filter name name**，创建URL过滤模板，并进入URL过滤模板视图。
 - 如果设备上已经存在URL过滤模板，为了提高配置效率，可以执行命令**profile type url-filter copy old-name [new-name]**，通过复制已经存在的URL过滤模板来创建新的URL过滤模板，并进入新URL过滤模板视图。

缺省情况下，未创建URL过滤模板。
 - c. （可选）执行命令**description description**，配置URL过滤模板的描述信息。

缺省情况下，未配置URL过滤模板的描述信息。
 - d. （可选）执行命令**https-filter enable**，开启加密流量过滤功能。

缺省情况下，关闭加密流量过滤功能。
 - e. 根据实际情况，将指定的URL添加到URL白名单或黑名单中。
 - 执行命令**add whitelist { url url-text | host host-text }**，向URL过滤模板中添加白名单规则。

- 执行命令**add blacklist { url *url-text* | host *host-text* }**，向URL过滤模板中添加黑名单规则。
- f. 执行命令**add referer-host *host-text***，向URL过滤配置文件中添加referer-host。

Router将HTTP请求中的referer字段与配置的referer-host进行匹配，如果匹配则允许该URL请求。如果HTTP请求中的referer字段没有匹配配置的referer-host，用户还可以选择是否将referer字段去匹配所有配置的白名单规则。

 - 当referer字段匹配白名单功能开启时，将referer字段与配置的所有白名单规则继续匹配。如果匹配命中，则允许该URL请求。
 - 当referer字段匹配白名单功能关闭时，不会将referer字段与配置的所有白名单继续匹配。

referer字段匹配白名单功能默认开启，用户也可以通过**undo referer-filter whitelist-all enable**命令关闭该功能。如果没有配置referer-host，并且referer字段匹配白名单功能开启，Router将HTTP请求中的referer字段与所有白名单规则进行匹配，如果匹配命中，则允许该URL请求。
- g. 执行命令**quit**，返回系统视图。
- h. 执行命令**engine configuration commit**，对URL过滤相关的配置进行提交。

----结束

后续处理

配置完成URL过滤模板后，为了方便记忆和管理，可以根据实际情况对URL自定义分类或URL过滤模板重新命名。

- 在URL过滤模板视图下，执行命令**rename *new-name***，对已存在的URL过滤模板进行重命名，并进入新的URL过滤模板视图。
- 在URL自定义分类视图下，执行命令**rename *new-name***，对已存在的URL自定义分类进行重命名，并进入新的URL自定义分类视图。

7.3.6.2 在安全策略下绑定 URL 过滤模板

前提条件

绑定URL过滤模板时，如果需要引用ACL，请确保已通过命令**acl（系统视图）**创建了ACL。

背景信息

安全策略是控制设备对流量进行内容安全一体化检测的策略。配置URL过滤模板后，需要在安全策略下绑定URL过滤模板，并在安全域间应用安全策略，设备才能根据URL过滤策略规范用户上网行为。

网络中存在多种业务流量，针对不同的业务流量，设备上也会配置多种安全策略。在安全策略下，可以同时绑定不同类型的模板，但是相同类型的模板只能绑定一个。

说明

如果需要同时配置多种内容安全保护功能（例如，需要同时配置URL过滤），请先配置好URL过滤模板，然后同时通过命令**profile**来在安全策略下绑定。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**security-policy policy-name**，创建安全策略并进入安全策略视图。

缺省情况下，未创建安全策略。

步骤3 执行命令**profile urlf urlf-name [acl acl-id]**，在安全策略下绑定URL过滤模板。

缺省情况下，安全策略下未绑定URL过滤模板。

说明

URL过滤模板在绑定ACL4时，需要在创建的ACL内配置双向rule规则，才能使配置生效。

----结束

7.3.6.3 在安全域间应用安全策略

前提条件

- 已创建安全区域并将接口加入了安全区域，具体请参见“防火墙配置”中的[6.6.1 创建安全域并将接口加入安全区域](#)。
- 已成功创建了安全域间，具体请参见“防火墙配置”中的[6.6.2 创建安全域间](#)。
- 已完成安全策略的配置，具体请参见[7.3.6.2 在安全策略下绑定URL过滤模板](#)。

背景信息

完成URL过滤的配置后，只有指定URL过滤规则应用的范围，才能让URL过滤功能生效。

目前，只有当不同安全区域之间发生数据流动时，才会触发安全检查。所以如果想让URL过滤功能生效，需要进入安全域间并在安全域间应用安全策略。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall interzone zone-name1 zone-name2**，创建安全域间并进入安全域间视图。

缺省情况下，未创建安全域间。

创建安全域间必须指定两个已存在的安全区域。

步骤3 执行命令**security-policy policy-name**，在安全域间绑定安全策略。

缺省情况下，安全域间未绑定安全策略。

应用安全策略后，如果安全策略下绑定URL过滤模板时未配置ACL，则设备会对所有安全域间的流量进行URL过滤检测；如果安全策略下绑定URL过滤模板时配置了ACL，则设备根据ACL里的rule，来确定是否对流量进行URL过滤检测。

- 如果ACL的rule配置为permit，设备会对匹配该规则的流量进行检测。
- 如果ACL的rule配置为deny，设备不会对匹配该规则的流量进行检测。
- 如果流量未匹配上ACL，设备也不对流量进行检测。

步骤4 执行命令**quit**，返回系统视图。

----结束

7.3.6.4 （可选）控制 URL 过滤的生成日志功能

背景信息

如果某一时刻大量用户的URL请求命中了对应URL黑名单、自定义分类或预定义分类，则URL过滤模块会在短时间内向设备上报大量的日志信息。如果设备实时输出日志，可能会造成刷屏，干扰管理员正常工作。

为了解决这个问题，可以选择配置日志缓存功能，控制URL过滤的日志发送频率；也可以选择直接关闭生成日志功能，使URL过滤模块不再上报日志。

说明

访问的URL域名长度超过63位字节会导致NetStream上报URL信息不完整，影响用户数据统计。

操作步骤

- 配置日志缓存功能
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**engine log url-filter enable**，使能URL过滤模块的生成日志功能。

缺省情况下，URL过滤模块的生成日志功能处于使能状态。
 - c. 执行命令**engine log timeout time**，配置URL过滤的日志缓存周期。

缺省情况下，URL过滤模块的日志缓存周期为1分钟。
- 关闭日志发送功能
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**undo engine log url-filter enable**，去使能URL过滤模块的生成日志功能。

缺省情况下，URL过滤模块的生成日志功能处于使能状态。

----结束

7.3.6.5（可选）基于用户组配置 URL 过滤

背景信息

由于Web网管支持基于用户组对用户进行管理，因此可以配置基于用户组的URL过滤。通过在用户组上绑定URL过滤模板并使能URL过滤功能，管理员可以对用户组内所有用户的上网行为进行统一管理，达到规范上网行为的目的。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**profile type url-filter name name**，创建URL过滤模板，并进入URL过滤模板视图。

缺省情况下，未配置URL过滤模板。

步骤3 执行命令**quit**，返回系统视图。

步骤4 执行命令**web**，进入Web视图。

步骤5 执行命令**user-set user-set-name**，创建一个Web用户组并进入Web用户组视图，或直接进入一个已存在的Web用户组视图。

缺省情况下，设备中存在两个Web用户组：一个名为VIP，一个名为Default。

步骤6 执行命令**quit**，返回Web视图。

步骤7 执行命令**web-url-filter user-set user-set-name profile profile-name [time-range time-range-name] [description description-text]**，或命令**enable web-url-filter user-set user-set-name**，使能基于用户组的URL过滤功能。

缺省情况下，基于用户组的URL过滤功能处于未使能状态。

步骤8 执行命令**quit**，返回系统视图。

----结束

7.3.6.6（可选）配置远程查询服务

调度中心（sec.huawei.com）可以提供诸多远程服务，设备需要正确配置相关参数，才能成功获得远程查询服务。

前提条件

如需使用远程查询服务，请确保已完成如下工作：

- 已配置DNS服务器地址，并可以正确解析sec.huawei.com。
- 设备与sec.huawei.com路由可达。
- 配置安全策略，允许以下自定义服务的流量通过设备。
 - TCP协议：目的端口为80（与调度中心进行交互）
 - TCP协议：目的端口为12612（与调度服务器进行交互）
 - UDP协议：目的端口为12600（与查询服务器进行交互）

说明

配置远程查询服务功能前，必须执行命令**install module**，安装设备内置的url-default.app组件，否则此功能不生效。

背景信息

一般来说，远程查询服务由调度中心、调度服务器和查询服务器共同完成。各设备的作用如下：

- 调度中心：调度中心的作用是对设备进行认证。如果认证通过，调度中心将根据设备所在的国家信息，向设备提供该区域内的调度服务器地址和端口。
和调度中心进行交互时，协议为TCP，目的端口为80。
- 调度服务器：调度服务器的作用是向设备提供区域内的查询服务器地址和端口。由于调度服务器是分区域部署的，所以设备上必须配置正确的国家信息，否则无法成功获取到调度服务器的地址和端口。
和调度服务器进行交互时，协议为TCP，目的端口为12612。
- 查询服务器：查询服务器的作用是处理查询请求，并将查询结果返回给设备。查询服务器也是分区域部署的，且和调度服务器存在配套关系，即调度服务器只能向设备提供同一区域内的查询服务器地址和端口。
和查询服务器进行交互时，协议为UDP，目的端口为12600。

按照服务器部署位置来划分，当前设备仅支持远程查询方式。远程模式下，设备与调度中心进行通信。调度服务器根据设备上配置的国家信息，转发查询请求给该国家内的查询服务器处理。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cloud-query remote url enable**，开启URL远程查询开关。

缺省情况下，URL远程查询开关是开启的。

步骤3 执行命令**country country-code**，配置设备所在的国家或地区信息。

缺省情况下，没有配置设备所在的国家信息。

步骤4 执行命令**dns resolve**，开启动态域名解析功能。

缺省情况下，动态域名解析功能处于关闭状态。

步骤5 执行命令**dns server ip-address**，配置DNS服务器地址。

请从运营商处获取DNS服务器的IP地址。

步骤6 执行命令**dns domain domain-name**，配置调度中心的域名。

缺省情况下，调度中心的域名为sec.huawei.com。

----结束

7.3.6.7 检查 URL 过滤配置结果

前提条件

已完成URL过滤功能的配置。

操作步骤

- 执行命令**display url-filter category pre-defined** [**category-id** *category-id* | **subcategory-id** *subcategory-id* | **url** *url-text* | **host** *host-text*], 查看URL分类列表信息。
- 执行命令**display url-filter category user-defined** [**name** *category-name* | **url** *url-text* | **host** *host-text*], 查看URL分类列表信息。
- 执行命令**display profile type url-filter**或**display profile type url-filter name** *name* [**blacklist** [**url** *url-text* | **host** *host-text*] | **whitelist** [**url** *url-text* | **host** *host-text*] | **pre-defined** [**category-id** *category-id* | **subcategory-id** *subcategory-id*] | **user-defined** [**name** *category-name*]], 查看URL过滤模板的信息。
- 执行命令**display cloud-query configuration**, 查看远程查询的全局配置信息, 检查相关配置是否正确下发, 以及远程查询服务是否正常。

----结束

7.3.7 维护 URL 过滤

维护URL过滤包括查看和清除URL过滤的统计信息。

7.3.7.1 查看 URL 过滤的统计信息

背景信息

当用户需要了解启用URL过滤功能后设备上允许和禁止的HTTP请求报文数、报文命中URL分类的次数等信息时, 可以查看URL过滤的统计信息。

操作步骤

- 执行命令**display url-filter statistics**, 查看当前URL过滤的统计信息。

----结束

7.3.7.2 清除 URL 过滤的统计信息

背景信息

当需要重新统计URL过滤信息时, 可以清除URL过滤的统计信息使设备重新开始进行统计。

须知

执行**reset**命令清除URL过滤的统计信息后, 所有的统计数据都不能被恢复, 请务必仔细确认。

操作步骤

- 执行命令 **reset url-filter statistics { blacklist | whitelist | category [user-defined | pre-defined] | all }**，清除URL过滤的统计信息。

----结束

7.3.8 URL 过滤配置举例

介绍URL过滤的配置举例。配置举例中包括组网需求、配置思路、操作步骤等。

7.3.8.1 配置 URL 过滤规范员工上网行为示例

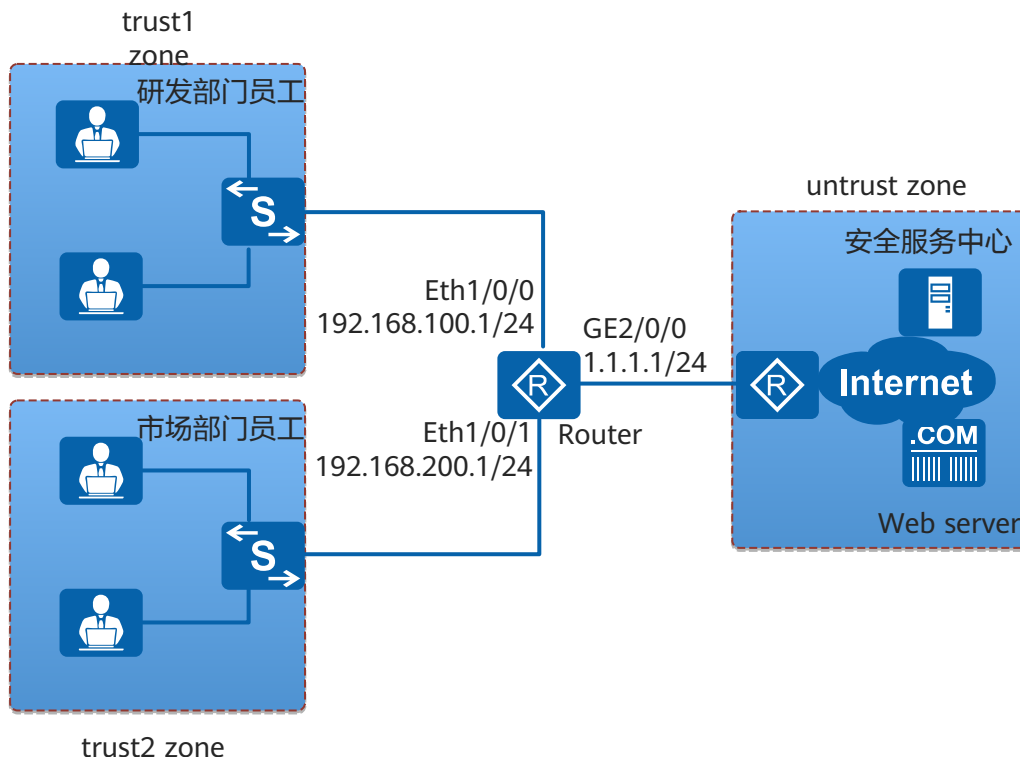
组网需求

如图7-13所示，Router作为网关设备部署在企业网出口处，规范用户通过HTTP访问网络资源的行为。

公司有研发部门员工和市场部门员工两类，具体需求如下：

- 所有员工都可以访问huawei.com网站。
- 所有员工都不可以访问youtube.com网站。
- 研发部门员工可以访问www.google.com网站，其他网站都不能访问。
- 市场部门员工在工作日的09：00～17：00只可以访问教育/科学类、搜索/门户类、社会焦点类网站。其他网站都不能访问。

图 7-13 配置 URL 过滤规范员工上网行为示例



配置思路

采用如下的思路配置URL过滤规范员工上网行为：

1. 将研发部门员工、市场部门员工和外部网络划分在三个安全区域trust1、trust2和untrust中，同时将各自的接口分别加入安全区域中，实现对研发部门员工和外部网络、市场部门员工和外部网络之间的网络流量的监控。
2. 针对研发部门员工，配置URL过滤模板research。
 - a. 将包含关键字huawei.com的URL列入白名单，允许所有用户访问。
 - b. 将包含关键字youtube.com的URL列入黑名单，禁止所有用户访问。
 - c. 将www.google.com加入到URL自定义分类并配置动作为允许。
 - d. 对URL分类中未覆盖到的Web网站进行URL过滤控制，配置动作为阻断。
3. 针对市场部门员工，配置URL过滤模板market。
 - a. 将包含关键字huawei.com的URL列入白名单，允许所有用户访问。
 - b. 将包含关键字youtube.com的URL列入黑名单，禁止所有用户访问。
 - c. 对本例中的教育/科学类、搜索/门户类、社会焦点类网站进行URL过滤控制，配置动作为允许。
 - d. 对URL分类中未覆盖到的Web网站进行URL过滤控制，配置动作为阻断。
4. 配置需要进行内容安全检测的对象，即检测的时间段范围。
5. 配置两个安全策略test1和test2，分别绑定URL过滤模板research和market，并通过引用对象，对网络流量进行内容安全检测。
6. 将安全策略test1应用于安全区域trust1和untrust之间，安全策略test2应用于安全域间trust2和untrust之间，达到控制用户上网的目的。

操作步骤

步骤1 本地升级业务感知特征库，该特征库默认存储在flash:/default-sdb/sa-sdb.zip上。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] engine enable
[Router] update local sa-sdb file flash:/default-sdb/sa-sdb.zip
```

步骤2 创建安全区域。

创建安全区域trust1、trust2和untrust。

```
[Router] firewall zone trust1
[Router-zone-trust1] priority 14
[Router-zone-trust1] quit
[Router] firewall zone trust2
[Router-zone-trust2] priority 10
[Router-zone-trust2] quit
[Router] firewall zone untrust
[Router-zone-untrust] priority 1
[Router-zone-untrust] quit
```

步骤3 配置各接口IP地址并将接口加入安全区域。

分别配置Ethernet1/0/0、Ethernet1/0/1和GE2/0/0接口的IP地址，将Ethernet1/0/0加入安全区域trust1，Ethernet1/0/1加入安全区域trust2，GE2/0/0加入安全区域untrust。

```
[Router] interface ethernet 1/0/0
[Router-Ethernet1/0/0] ip address 192.168.100.1 24
[Router-Ethernet1/0/0] zone trust1
[Router-Ethernet1/0/0] quit
[Router] interface ethernet 1/0/1
[Router-Ethernet1/0/1] ip address 192.168.200.1 24
[Router-Ethernet1/0/1] zone trust2
[Router-Ethernet1/0/1] quit
[Router] interface gigabitethernet 2/0/0
[Router-GigabitEthernet2/0/0] ip address 1.1.1.1 24
[Router-GigabitEthernet2/0/0] zone untrust
[Router-GigabitEthernet2/0/0] quit
```

步骤4 配置URL过滤功能。

配置URL自定义分类url_userdefine_category并将www.google.com加入到该分类。

```
[Router] url-filter category user-defined name url_userdefine_category
[Router-category-user-defined-url_userdefine_category] add url www.google.com
[Router-category-user-defined-url_userdefine_category] quit
```

配置URL过滤模板research，为研发部门员工提供URL过滤策略。

```
[Router] profile type url-filter name research
[Router-profile-url-filter-research] add whitelist url *huawei.com*
[Router-profile-url-filter-research] add blacklist url *youtube.com*
[Router-profile-url-filter-research] category pre-defined action block
[Router-profile-url-filter-research] category user-defined action block
[Router-profile-url-filter-research] category user-defined name url_userdefine_category action allow
[Router-profile-url-filter-research] default action block
[Router-profile-url-filter-research] quit
```

配置URL过滤模板market，为市场部门员工提供URL过滤策略。

说明

已通过命令**display url-filter category pre-defined**查看到社会焦点类（Social Focus）、搜索/门户类（Search Engines/Portals）、教育/科学类（huawei.com/Science）的大类ID为5、15和17。

对预定义分类进行配置时，需要在系统视图下执行**import url-sdb file**命令将URL预分类库导入到设备的缓存，URL预分类库默认存储在flash:/default-sdb/url.sdb上，即执行命令**import url-sdb file flash:/default-sdb/url.sdb**。

```
[Router] profile type url-filter name market
[Router-profile-url-filter-market] add whitelist url *huawei.com*
[Router-profile-url-filter-market] add blacklist url *youtube.com*
[Router-profile-url-filter-market] category pre-defined action block
[Router-profile-url-filter-market] category pre-defined category-id 5 action allow
[Router-profile-url-filter-market] category pre-defined category-id 15 action allow
[Router-profile-url-filter-market] category pre-defined category-id 17 action allow
[Router-profile-url-filter-market] default action block
[Router-profile-url-filter-market] quit
```

步骤5 配置需要进行内容安全检测的对象。

配置对每周一到周五的9:00至17:00时间段内所有通过设备的流量进行内容安全检测。

```
[Router] time-range test 09:00 to 17:00 working-day
[Router] acl 2000
[Router-acl-basic-2000] rule 5 permit time-range test
[Router-acl-basic-2000] quit
```

步骤6 在安全策略下绑定URL过滤模板。

创建安全策略test1并在test1下绑定URL过滤模板research。

```
[Router] security-policy test1
[Router-security-policy-test1] profile urlf research
[Router-security-policy-test1] quit
```

创建安全策略test2并在test2下绑定URL过滤模板market。

```
[Router] security-policy test2
[Router-security-policy-test2] profile urlf market acl 2000
[Router-security-policy-test2] quit
```

步骤7 在安全域间应用安全策略。

在trust1和untrust的安全域间下应用安全策略test1。

```
[Router] firewall interzone trust1 untrust
[Router-interzone-trust1-untrust] security-policy test1
[Router-interzone-trust1-untrust] quit
```

在trust2和untrust的安全域间下应用安全策略test2。

```
[Router] firewall interzone trust2 untrust
[Router-interzone-trust2-untrust] security-policy test2
[Router-interzone-trust2-untrust] quit
```

步骤8 提交配置。

```
[Router] engine configuration commit
```

步骤9 验证配置结果。

- 任何员工都能访问huawei.com的网站。
- 任何员工都不能访问youtube.com的网站。
- 研发部门员工能访问www.google.com和huawei.com网站。其他网站都不能访问。
- 市场部门员工在09:00~17:00之间，可以访问教育/科学类、搜索/门户类、社会焦点类和huawei.com网站。其他网站都不能访问。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
time-range test 09:00 to 17:00 working-day
#
engine enable
#
acl number 2000
rule 5 permit time-range test
#
url-filter category user-defined name url_userdefine_category
add url www.google.com
#
profile type url-filter name research
add blacklist url *youtube.com*
add whitelist url *huawei.com*
.....
default action block
profile type url-filter name market
add blacklist url *youtube.com*
add whitelist url *huawei.com*
category pre-defined subcategory-id 101 action block
category pre-defined subcategory-id 102 action block
```

```
category pre-defined subcategory-id 162 action block
.....
default action block
#
security-policy test1
  profile urlf research
security-policy test2
  profile urlf market acl 2000
#
firewall zone trust2
  priority 10
#
firewall zone untrust
  priority 1
#
firewall zone trust1
  priority 14
#
firewall interzone trust1 untrust
  security-policy test1
#
firewall interzone trust2 untrust
  security-policy test2
#
interface Ethernet1/0/0
  ip address 192.168.100.1 255.255.255.0
  zone trust1
#
interface Ethernet1/0/1
  ip address 192.168.200.1 255.255.255.0
  zone trust2
#
interface GigabitEthernet2/0/0
  ip address 1.1.1.1 255.255.255.0
  zone untrust
#
return
```

相关资料

视频：[禁止访问指定网站](#)

7.4 反病毒配置（AV）

7.4.1 反病毒简介

简介

介绍反病毒特性的定义和目的。

定义

病毒是一种恶意代码，可感染或附着在应用程序或文件中，一般通过邮件或文件共享等协议进行传播，威胁用户主机和网络的安全。有些病毒会耗尽主机资源、占用网络带宽，有些病毒会控制主机权限、窃取数据，有些病毒甚至会对主机硬件造成破坏。

反病毒是一种安全机制，它可以通过识别和处理病毒文件来保证网络安全，避免由病毒文件而引起的数据破坏、权限更改和系统崩溃等情况的发生。

目的

随着网络的不断发展和应用程序的日新月异，企业用户越来越频繁地开始在网络上传输和共享文件，随之而来的病毒威胁也越来越大。企业只有拒病毒于网络之外，才能保证数据的安全，系统的稳定。因此，保证计算机和网络系统免受病毒的侵害，让系统正常运行便成为企业所面临的一个重要问题。

反病毒功能可以凭借庞大且不断更新的病毒特征库有效地保护网络安全，防止病毒文件侵害系统数据。将病毒检测设备部署在企业网的入口，可以真正将病毒抵御于网络之外，为企业网络提供一个坚固的保护层。

7.4.2 反病毒应用场景

应用场景

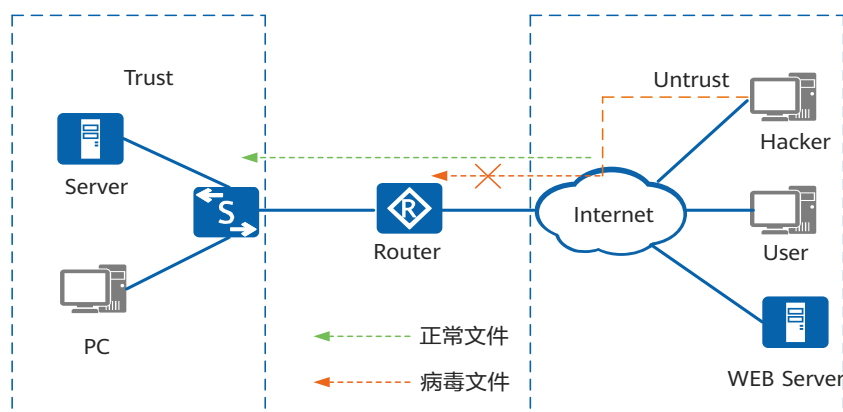
介绍反病毒特性的应用场景。

在以下场合中，通常利用反病毒特性来保证网络安全：

- 内网用户可以访问外网，且经常需要从外网下载文件。
- 内网部署的服务器经常接收外网用户上传的文件。

如图1所示，AR作为网关设备隔离内、外网，内网包括用户PC和服务器。内网用户可以从外网下载文件，外网用户可以上传文件到内网服务器。为了保证内网用户和服务器接收文件的安全，需要在AR上配置反病毒功能。

图 7-14 反病毒典型应用场景



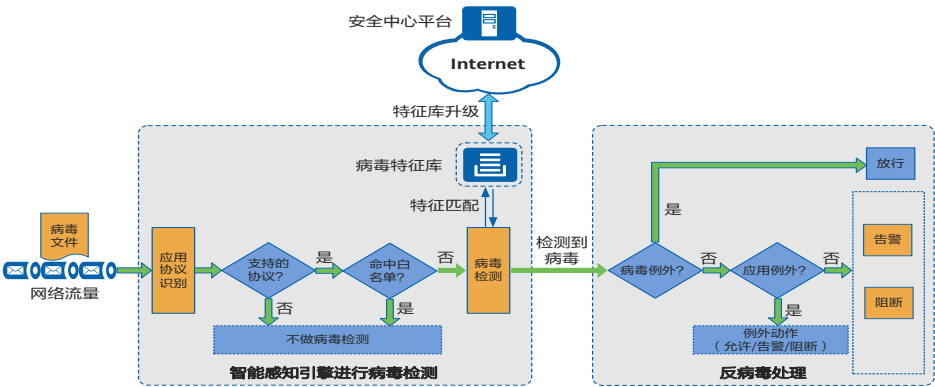
7.4.3 反病毒原理描述

原理描述

介绍反病毒特性的实现原理和处理流程。

AR利用专业的智能感知引擎和不断更新的病毒特征库实现对病毒文件的检测和处理，其工作原理如图1所示。

图 7-15 反病毒工作原理



智能感知引擎进行病毒检测

- AR的病毒检测是依靠智能感知引擎来进行的。流量进入智能感知引擎后：
- 首先智能感知引擎对流量进行深层分析，识别出流量对应的协议类型和文件传输的方向。
 - 判断文件传输所使用的协议和文件传输的方向是否支持病毒检测。
AR支持对使用以下协议传输的文件进行病毒检测：
 - FTP（File Transfer Protocol）：文件传输协议
 - HTTP（Hypertext Transfer Protocol）：超文本传输协议
 - POP3（Post Office Protocol - Version 3）：邮局协议的第3个版本
 - SMTP（Simple Mail Transfer Protocol）：简单邮件传输协议
 - IMAP（Internet Message Access Protocol）：因特网信息访问协议
 - NFS（Network File System）：网络文件系统
 - SMB（Server Message Block）：文件共享服务器AR支持对不同传输方向上的文件进行病毒检测。
 - 上传：指从trust区域向untrust区域发送文件。
 - 下载：指从trust区域向untrust区域获取文件。
 - 判断是否命中白名单。
命中白名单后，AR将不对文件做病毒检测。

说明

白名单只能通过命令行方式配置，不能在Web界面上配置。
白名单由白名单规则组成，管理员可以为信任的域名、URL、IP地址或IP地址段配置白名单规则，以此提高反病毒的检测效率。白名单规则的生效范围仅限于所在的反病毒配置文件，每个反病毒配置文件都拥有自己的白名单。
针对域名和URL，白名单规则有以下4种匹配方式：

- 前缀匹配: *host-text*或*url-text*配置为“example*”的形式, 即只要域名或URL的前缀是“example”就命中白名单规则。
 - 后缀匹配: *host-text*或*url-text*配置为“*example”的形式, 即只要域名或URL的后缀是“example”就命中白名单规则。
 - 关键字匹配: *host-text*或*url-text*配置为“*example*”的形式, 即只要域名或URL中包含“example”就命中白名单规则。
 - 精确匹配: 域名或URL必须与*host-text*或*url-text*完全一致, 才能命中白名单规则。
4. 病毒检测。

智能感知引擎对符合病毒检测的文件进行特征提取, 提取后的特征与病毒特征库中的特征进行匹配。如果匹配, 则认为该文件为病毒文件, 并按照配置文件中的响应动作进行处理。如果不匹配, 则允许该文件通过。

病毒特征库是由华为公司通过分析各种常见病毒特征而形成的。该特征库对各种常见的病毒特征进行了定义, 同时为每种病毒特征都分配了一个唯一的病毒ID。当设备加载病毒特征库后, 即可识别出特征库里已经定义过的病毒。同时, 为了能够及时识别出最新的病毒, 设备上的病毒特征库需要不断地从升级中心进行升级。

说明

病毒特征库的升级服务需要购买相关的License后才能正常使用。

反病毒处理

当AR检测出传输文件为病毒文件时, 需要进行如下处理:

1. 判断该病毒文件是否命中病毒例外。如果是病毒例外, 则允许该文件通过。
为了避免由于系统误报等原因造成文件传输失败等情况的发生, 当用户认为已检测到的某个病毒为误报时, 可以将该对应的病毒ID添加到病毒例外, 使该病毒规则失效。如果检测结果命中了病毒例外, 则该文件的响应动作为放行。
2. 如果不是病毒例外, 则判断该病毒文件是否命中应用例外。如果是应用例外, 则按照应用例外的响应动作（放行、告警和阻断）进行处理。
应用例外可以为应用配置不同于协议的响应动作。应用承载于协议之上, 同一协议上可以承载多种应用。例如, HTTP协议上可以承载163.com的应用, 也可以承载yahoo.com的应用。
由于应用和协议之间存在着这样的关系, 在配置响应动作时也有如下规定:
 - 如果只配置协议的响应动作, 则协议上承载的所有应用都继承协议的响应动作。
 - 如果协议和应用都配置了响应动作, 则以应用的响应动作为准。例如, HTTP协议上承载了“163.com”和“yahoo.com”两种应用:
 - 如果只配置了HTTP协议的响应动作为“阻断”, 则“163.com”和“yahoo.com”的响应动作也都继承为“阻断”。
 - 如果用户希望对“163.com”这个应用做区分处理, 则可以将“163.com”添加为“应用例外”, 其响应动作为“告警”。此时, “yahoo.com”的响应动作仍然继承HTTP协议的响应动作“阻断”, 而“163.com”的响应动作将使用应用例外的响应动作“告警”。
3. 如果病毒文件既没命中病毒例外, 也没命中应用例外, 则按照配置文件中配置的协议和传输方向对应的响应动作进行处理。
AR对不同协议在不同的文件传输方向上支持不同的响应动作, 如下所示。

协议	传输方向	响应动作	说明
HTTP	上传/下载	告警/阻断，默认为阻断。	- 告警：允许病毒文件通过，同时生成病毒日志。 - 阻断：禁止病毒文件通过，同时生成病毒日志。
FTP	上传/下载	告警/阻断，默认为阻断。	
NFS	上传/下载	告警	
SMB	上传/下载	告警/阻断，默认为阻断。	
SMTP	上传	告警，默认为告警。	
POP3	下载	告警，默认为告警。	
IMAP	上传/下载	告警，默认为告警。	

7.4.4 反病毒配置注意事项

涉及网元

无

License 支持

表 7-12 反病毒支持的 License 列表

系列	License支持情况
AR300&AR700系列	AR720和AR730无需获得License许可即可应用该功能。

硬件依赖

表 7-13 反病毒硬件依赖

系列	特性支持情况
AR300&AR700系列	仅AR720和AR730支持反病毒。

特性依赖和限制

- 只支持基于流AV功能。

- 仅FTP、HTTP支持针对断点续传文件的反病毒检测。
- 不支持IPv6的病毒检测。
- 反病毒License未激活时，只有基本功能可以配置，不支持升级特征库。
- 不支持对SFTP、HTTPS、SMTPS、POP3S或IMAPS流量进行反病毒检测。
- 不支持AV攻击取证。
- 压缩文件只支持tar、gzip、zip压缩。
- 不支持邮件代理，邮件不能阻断。
- 反病毒特征库更新频繁，为保证反病毒功能的有效性，推荐每天升级一次反病毒特征库。
- 在报文来回路径不一致的组网环境中，针对SMTP、POP3和IMAP协议的反病毒功能不可用。
- 部署在两台路由设备中间，且两台路由设备通过BFD互相探测时，建议将路由设备上的BFD检测时间适当调大（建议大于100ms），避免网络偶发性拥塞时导致BFD震荡。

7.4.5 开启深度安全防御功能

背景信息

如果需要使用IPS功能、URL过滤或者AV反病毒功能，除购买对应License外，同时还需要通过执行**engine enable**命令开启深度安全防御功能。

开启深度安全功能后，如果需要关闭该功能，请执行命令**undo engine enable**并重启设备，关闭深度安全功能才生效。重启后，有关深度安全的配置将不存在。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**engine enable**，开启深度安全防御功能。

缺省情况下，系统未开启深度安全防御功能。

----结束

7.4.6 升级反病毒特征库

前提条件

升级反病毒特征库前，请确认已购买并成功激活支持反病毒特征库升级服务的License。

具体操作如下：

执行命令**display license**，查看待升级特征库的License是否被激活，是否过期。

- 如果待升级特征库对应的状态为“Disabled”，则需要激活License，具体操作请参见《AR300, AR700 License使用指南-安装License使用指南》中的全新场景License指导。
- 如果待升级特征库对应的状态为“Enabled”，则需要确认是否过期。如果过期请重新购买相应的License。

背景信息

反病毒特征库的升级方式有：

- 在线升级
当设备能访问安全中心平台时，可以配置通过安全中心平台进行在线升级。
- 本地升级
当设备无法访问安全中心平台时，用户可以在能够访问安全中心平台的PC上下载升级包，通过FTP或TFTP等方式将反病毒特征库文件上传到设备上上进行本地升级。

说明

当设备更换启动路径时，用户需要再次通过在线升级或本地升级的方式加载特征库。

操作步骤

- 在线升级
 - a. 执行命令**system-view**，进入系统视图。
 - b. （可选）执行命令**update server { domain domain-name | ip ip-address } [port port-number]**，配置升级服务器的IP地址或者域名。

缺省情况下，升级服务器的域名为sec.huawei.com，HTTP协议的端口号为80，HTTPS协议的端口号为443。

- c. （可选）执行命令**update download-server aging-time age-time**，配置下载服务器的老化时间。缺省情况下，下载服务器的老化时间为7天。

说明

下载服务器的老化时间仅对HTTPS升级方式生效，对HTTP升级方式不生效。

- d. （可选）通过代理服务器访问升级服务器。
 - i. 执行命令**update proxy enable**，开启特征库代理升级功能。
缺省情况下，设备没有开启特征库代理升级功能。
 - ii. 执行命令**update proxy { domain domain-name | ip ip-address } [port port-number] [user user-name [password password]]**，配置代理服务器的IP地址或者域名。
- e. 确定在线升级方式
 - 通过安全中心平台进行在线升级
为保证设备能访问安全中心平台，需要配置动态域名解析功能。
 - 1) 执行命令**dns resolve**，启用DNS服务器的域名解析功能。
 - 2) 执行命令**dns server ip-address**，配置DNS服务器的IP地址。
 - 定时升级
 - i. 执行命令**update schedule av-sdb enable**，开启反病毒特征库的定时升级功能。
缺省情况下，已开启反病毒特征库定时升级功能。
 - ii. 执行命令**update schedule [{ daily | weekly { Mon | Tue | Wed | Thu | Fri | Sat | Sun } } time]**，配置反病毒特征库定时在线下载时间。

如果未配置定时下载时间，则缺省在22:00~08:00之间随机选择一个时间作为每天进行定时升级的时间。

*time*建议设置为一天中设备流量最小的时间，例如凌晨6点前后。

iii. 配置反病毒特征库安装方式

反病毒特征库下载后，还需要在设备上安装才生效。用户可以选择是否使能安装确认功能，即定时升级的反病毒特征库是否需要经过用户确认后再安装。

反病毒特征库安装时涉及新旧反病毒特征库的切换，可能影响入侵行为的检测，用户可以选择影响较小时启用安装确认功能。

○ 用户确认后安装

- 1) 执行命令**update confirm av-sdb enable**，使能安装确认功能，即定时下载的反病毒特征库需要经过用户确认后再安装。
缺省情况下，关闭特征库安装确认功能，即设备下载升级文件后自动进行安装。
- 2) 执行命令**update apply av-sdb**，安装下载的反病毒特征库。

○ 用户无需确认即直接安装

执行命令**undo update confirm av-sdb enable**，去使能安装确认功能，即定时下载的反病毒特征库进行自动安装，不需要经过用户确认。

f. （可选）立即升级

用户一般可选择定时升级。如果发现网络上出现新的入侵行为，而设备的定时升级时间尚未达到时，用户可以执行立即升级。

- i. 执行命令**update online av-sdb**，立即升级反病毒特征库。
- ii. 执行命令**update apply av-sdb**，安装升级的反病毒特征库。

● 终止升级

在用户开始升级后，发现升级过程占用了较大网络资源，可以终止升级。

 说明

只有在下载阶段才可以终止升级。

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**update abort**，用来终止升级。

● 回退版本

如果升级后的特征库出现问题或不符合用户预期，用户可使用该命令回退到上一个版本。

 说明

进行版本回退前，建议先使用**display version av-sdb**命令查看可回退版本信息，再决定是否要进行版本回退。如果不存在可回退版本，版本回退将失败，设备中仍然是回退前的版本。

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**update rollback av-sdb**，回退反病毒特征库到上一个版本。

● 本地升级

- a. 执行命令**system-view**，进入系统视图。

- b. 执行命令**update local av-sdb file filename**，进行本地升级反病毒特征库。

说明

本地升级不支持**终止升级**。

- 恢复出厂默认版本

说明

特征库恢复到出厂默认版本后，设备上其他所有反病毒特征库均被删除。

- a. 执行命令**system-view**，进入系统视图。
- b. 执行命令**update restore sdb-default av-sdb**，将特征库恢复到出厂默认版本。

----结束

操作结果

- 执行命令**display engine information**，查看引擎的运行状态和特征库的版本信息。
- 执行命令**display version av-sdb**，查看升级后反病毒特征库的版本信息。
- 执行命令**display update status**，查看升级的状态。
- 执行命令**display update configuration**，查看升级配置信息。

7.4.7 配置反病毒

说明

配置AV反病毒功能前，需执行命令**sa application-statistic enable**使能接口的SA统计功能，否则功能不生效。

7.4.7.1 创建反病毒配置文件模板

介绍反病毒特性的配置步骤。

背景信息

设备中存在一个反病毒的缺省配置文件，名称为default。缺省配置文件中已经定义了每种协议在上传或下载方向上的缺省动作，如下所示。缺省配置文件不能被修改和删除。

说明

通过命令**display profile type av default**可以查看到缺省配置文件中的配置信息。通过命令行配置安全策略引用缺省配置文件时，需要输入完整的配置文件名称（如**default**），否则无法成功引用。如需查看配置结果，可以使用命令**display current-configuration**，在显示信息中可查看到安全策略引用了缺省配置文件，但是缺省配置文件自身的配置信息并不显示。

表 7-14 反病毒的缺省配置文件

名称	协议	上传方向的病毒检测	下载方向的病毒检测	缺省的动作
default	HTTP	开启	开启	阻断
	FTP	开启	开启	阻断
	SMTP	开启	-	告警
	POP3	-	开启	告警
	IMAP	开启	开启	告警
	NFS	开启	开启	告警
	SMB	开启	开启	阻断
应用例外：未配置				

AR支持创建自定义配置文件，您可以根据需要，对每种协议应用不同的响应动作。

操作步骤

- 步骤1 执行命令**system-view**，进入系统视图。
- 步骤2 在系统视图下创建反病毒配置文件。
 - 创建一个空配置的反病毒配置文件模板。
执行命令**profile type av name name**，创建反病毒配置文件并进入反病毒配置文件视图。
 - 复制方式创建反病毒配置文件模板。
执行命令**profile type av copy old-name [new-name]**，复制已经存在的反病毒配置文件来创建新的反病毒配置文件，并进入新的反病毒配置文件视图。
*old-name*是一个已创建的反病毒配置文件模板。缺省情况下，设备上存在反病毒配置文件模板，名称为**default**。
- 说明

为了方便记忆和管理，可以根据实际情况对反病毒配置文件进行重新命名。
执行命令**rename new-name**，对已存在的反病毒配置文件进行重命名，并且进入重命名后的反病毒配置文件视图。
- 步骤3 （可选）执行命令**description description**，配置反病毒配置文件描述信息。
缺省情况下，配置反病毒配置文件模板下未配置描述信息。
- 步骤4 配置需要检测病毒的协议类型、流量方向以及检测到病毒后的响应动作。

协议	命令
HTTP	http-detect direction { both download upload } [action { alert block }]
FTP	ftp-detect direction { both download upload } [action { alert block }]
SMTP	smtp-detect [action alert]
POP3	pop3-detect [action alert]
IMAP	imap-detect direction { both download upload } [action alert]
NFS	nfs-detect direction { both download upload }
SMB	smb-detect direction { both download upload } [action { alert block }]

步骤5 （可选）执行命令**exception application name** *name* [**action** { alert | allow | block }]，配置应用例外功能，为指定应用传输的文件配置例外响应动作。

缺省情况下，未配置应用例外功能。

步骤6 （可选）执行命令**whitelist** { **host** *host-text* | **url** *url-text* | **source-address** { *ip-address* | **range** *start-ip-address end-ip-address* } | **destination-address** { *ip-address* | **range** *start-ip-address end-ip-address* } }，配置反病毒的白名单规则。

缺省情况下，未配置反病毒的白名单规则。

----结束

后续处理

反病毒配置文件配置完成后，可以使用如下方式进行调整：

- 在反病毒配置文件视图执行**rename new-name**命令重命名已经存在的反病毒配置文件。
- 在系统视图下执行**profile type av copy old-name [new-name]**命令通过复制已经存在的反病毒配置文件来创建新的反病毒配置文件。

7.4.7.2 在安全策略下绑定反病毒配置文件模板

背景信息

安全策略是控制设备对流量转发以及对流量进行内容安全一体化检测的策略。启用AV功能后，需要在安全策略下绑定反病毒配置文件模板，并在安全域间应用安全策略，设备根据安全策略进行入侵防御。

网络中存在多种业务流量，针对不同的业务流量，设备上也会配置多条安全策略。在安全策略下，可以同时绑定不同类型的模板，但是相同类型的模板只能绑定一个。为了保证安全策略配置的正确性，管理员需要在配置安全策略前，完成安全策略的规划。

说明

如果需要同时配置多种内容安全保护功能（例如，需要同时配置IPS功能和反病毒功能），请先配置好IPS模板和反病毒模板，然后通过命令**profile**来在安全策略下绑定。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**security-policy policy-name**，用来创建安全策略，并进入安全策略视图。
缺省情况下，未创建安全策略。

步骤3 执行命令**profile av av-name [acl acl-id]**，用来配置安全策略下绑定的反病毒配置文件模板。

缺省情况下，未在安全策略上绑定反病毒配置文件模板。

*acl-id*是一个已创建的ACL。

目前，AV仅支持绑定ACL4，不支持ACL6。

说明

反病毒在绑定ACL4时，需要在创建的ACL内配置双向rule规则，才能使配置生效。

----结束

7.4.7.3 在安全域间应用安全策略

前提条件

已创建安全区域并将接口加入了安全区域，具体请参见“防火墙配置”中的[6.6.1 创建安全域并将接口加入安全区域](#)。

背景信息

完成安全策略的配置后，只有指定安全策略应用的范围，才能让安全策略生效。设备认为在同一安全区域内部发生的数据流动是可信的，不需要实施任何安全策略。只有当不同安全区域之间发生数据流动时，才会触发安全检查，并实施相应的安全策略。用户需要配置反病毒业务时，需要进入安全域间并在安全域间应用已绑定反病毒配置文件模板的安全策略。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**firewall interzone zone-name1 zone-name2**，创建安全域间并进入安全域间视图。

创建安全域间必须指定两个已存在的安全区域。

安全域间的具体信息，请参见“防火墙配置”中的[6.6.2 创建安全域间](#)。

步骤3 执行命令**security-policy policy-name**，在安全域间应用安全策略。

缺省情况下，安全域间未应用安全策略。

应用安全策略后，如果安全策略下绑定反病毒配置文件模板时未配置ACL，则设备会对所有安全域间的流量进行反病毒检测；如果安全策略下绑定反病毒配置文件模板时配置了ACL，则设备根据ACL里的rule，来确定是否对流量进行AV检测。

- 如果ACL的rule配置为permit，设备会对匹配该规则的流量进行检测。
- 如果ACL的rule配置为deny，设备不会对匹配该规则的流量进行检测。
- 如果流量未匹配上ACL，设备也不对流量进行检测。

----结束

7.4.7.4 （可选）控制反病毒的日志发送功能

背景信息

当某一时刻发生大量入侵行为，导致反病毒频繁触发告警和阻断，则反病毒会在短时间内向设备上报大量的日志信息。默认情况下，设备会实时输出日志，可能会造成刷屏，干扰管理员正常工作。

为了解决这个问题，可以关闭日志发送功能，也可以配置日志缓存功能，控制反病毒的日志发送频率。

日志缓存最大记录1024条日志，每次最多输出16条日志，输出日志从缓存中清空。默认情况下每1分钟定时输出。

说明

当日志缓存记录已满时，超出部分的日志会丢弃。如果配置的定时输出时间过长，导致日志缓存记录已满，可适当调小定时输出时间。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**engine log av enable**，用来开启指定或所有模块的发送日志功能。

缺省情况下，系统开启所有模块的发送日志功能。

步骤3 执行命令**engine log timeout interval**，配置日志输出频率。

缺省情况下，每1分钟定时输出。

步骤4 执行命令**av log merge enable**，开启反病毒日志归并功能。

缺省情况下，反病毒日志归并功能处于开启状态。

----结束

7.4.7.5 检查反病毒功能配置结果

操作步骤

- 执行命令**display av-signature** { *av-signature-id* | **database** }, 查看反病毒特征库中病毒家族或指定序号的病毒签名。
- 执行命令**display profile type av** [*name name* [**protocol** | **exception** { **application** | **av-signature-id** } | **whitelist** [**host** | **url** | **source-address** | **destination-address**]]], 查看反病毒配置文件信息。

----结束

7.4.8 维护反病毒

7.4.8.1 查看反病毒统计信息

背景信息

当入侵检测到的告警事件和阻断事件的情况时，用户可以查看快速扫描模式下的反病毒功能的统计信息，包括各个应用的事件统计信息、流量统计信息和文件统计信息。

操作步骤

- 执行命令**display av statistics**，查看快速扫描模式下的反病毒统计信息。

----结束

7.4.8.2 清除反病毒统计信息

背景信息

反病毒特性配置完成后，可执行如下操作清除统计信息：

须知

清除反病毒的统计信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

- 执行命令**reset av statistics**，清除快速扫描模式下的反病毒统计信息。

----结束

7.4.9 反病毒配置举例

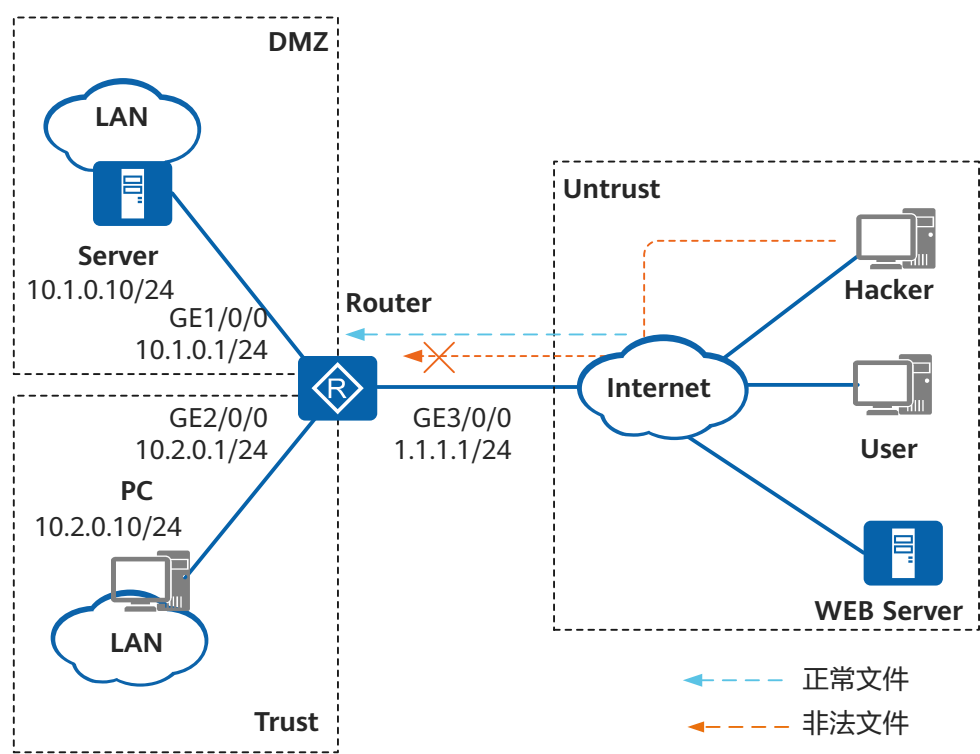
7.4.9.1 配置反病毒阻断入侵行为示例

组网需求

如图1所示，企业部署了Router作为安全网关。其中，企业员工所在内网用户部署在Trust区域，内网服务器部署在DMZ区域。

为了防止内网用户和内网服务器受到可感染或附着在应用程序或文件中的恶意代码入侵行为的攻击，需要对不同区域之间的流量进行安全检测，并及时阻断入侵行为，保护公司内部网络安全。

图 7-16 配置反病毒阻断入侵行为组网图



配置思路

- 采用如下的思路配置反病毒阻断入侵行为：
1. 配置相关接口的IP地址和路由，保证路由互通。
 2. 将内网服务器、内网用户和外部网络划分在三个安全区域DMZ、Trust和Untrust中，实现对不同安全区域之间的网络流量的监控。
 3. 针对内网用户，配置反病毒配置文件profile_av_pc。
 - a. 检测并防御通过HTTP、FTP协议传输的病毒文件。
 - b. 检测并防御目标是客户端的病毒文件。
 4. 针对内网服务器，配置反病毒配置文件profile_av_server。
 - a. 检测并防御协议通过HTTP、FTP协议传输的病毒文件。
 - b. 检测并防御目标是服务器的病毒。
 5. 配置需要进行内容安全检测的对象。

- 配置两个安全策略policy_sec_1和policy_sec_2，分别绑定反病毒配置文件profile_av_pc和profile_av_server，以对网络流量进行对应的内容安全检测。
- 在Trust到Untrust域间应用安全策略policy_sec_1，使安全策略生效，保护内网用户免受来自Internet的攻击。
- 在Untrust到DMZ域间以及Trust到DMZ域间应用安全策略policy_sec_2，使安全策略生效，保护内网服务器免受来自内网用户和Internet的攻击。

说明

配置AV反病毒功能前，需执行命令**sa application-statistic enable**使能接口的SA统计功能，否则功能不生效。

操作步骤

步骤1 在Router上配置安全区域和安全域间。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] engine enable
[Router] firewall zone DMZ
[Router-zone-DMZ] priority 14
[Router-zone-DMZ] quit
[Router] firewall zone Trust
[Router-zone-Trust] priority 13
[Router-zone-Trust] quit
[Router] firewall zone Untrust
[Router-zone-Untrust] priority 1
[Router-zone-Untrust] quit
[Router] firewall interzone Trust Untrust
[Router-interzone-Trust-Untrust] quit
[Router] firewall interzone DMZ Trust
[Router-interzone-DMZ-Trust] quit
[Router] firewall interzone DMZ Untrust
[Router-interzone-DMZ-Untrust] quit
```

步骤2 在Router上配置接口IP地址，并将接口加入安全区域。

```
[Router] interface gigabitethernet 1/0/0
[Router-GigabitEthernet1/0/0] ip address 10.1.0.1 24
[Router-GigabitEthernet1/0/0] zone DMZ
[Router-GigabitEthernet1/0/0] quit
[Router] interface gigabitethernet 2/0/0
[Router-GigabitEthernet2/0/0] ip address 10.2.0.1 24
[Router-GigabitEthernet2/0/0] zone Trust
[Router-GigabitEthernet2/0/0] quit
[Router] interface gigabitethernet 3/0/0
[Router-GigabitEthernet3/0/0] ip address 1.1.1.1 24
[Router-GigabitEthernet3/0/0] zone Untrust
[Router-GigabitEthernet3/0/0] quit
```

步骤3 配置反病毒配置文件profile_av_pc，检测并防御通过HTTP、FTP协议传输的病毒文件，保护内网用户。

```
[Router] profile type av name profile_av_pc
[Router-profile-av-profile_av_pc] http-detect direction upload action block
[Router-profile-av-profile_av_pc] ftp-detect direction upload action block
[Router-profile-av-profile_av_pc] quit
```

步骤4 配置反病毒配置文件profile_av_server，检测并防御通过HTTP、FTP协议传输的病毒文件，保护内部网络服务器。

```
[Router] profile type av name profile_av_server
[Router-profile-av-profile_av_server] http-detect direction upload action block
[Router-profile-av-profile_av_server] ftp-detect direction upload action block
[Router-profile-av-profile_av_server] quit
[Router] engine configuration commit
```

步骤5 创建安全策略policy_sec_1，并引用反病毒模板profile_av_pc。

```
[Router] security-policy policy_sec_1
[Router-security-policy-policy_sec_1] profile av profile_av_pc
[Router-security-policy-policy_sec_1] quit
```

步骤6 创建安全策略policy_sec_2，并引用反病毒模板profile_av_server。

```
[Router] security-policy policy_sec_2
[Router-security-policy-policy_sec_2] profile av profile_av_server
[Router-security-policy-policy_sec_2] quit
```

步骤7 在Trust到Untrust域间应用安全策略policy_sec_1，使安全策略生效，保护内网用户免受来自Internet的攻击。

```
[Router] firewall interzone Trust Untrust
[Router-interzone-Trust-Untrust] security-policy policy_sec_1
[Router-interzone-Trust-Untrust] quit
```

步骤8 在DMZ到Untrust域间以及DMZ到Trust域间应用安全策略policy_sec_2，使安全策略生效，保护内网服务器免受来自内网用户和Internet的攻击。

```
[Router] firewall interzone DMZ Untrust
[Router-interzone-DMZ-Untrust] security-policy policy_sec_2
[Router-interzone-DMZ-Untrust] quit
[Router] firewall interzone DMZ Trust
[Router-interzone-DMZ-Trust] security-policy policy_sec_2
[Router-interzone-DMZ-Trust] quit
```

步骤9 验证配置结果。

在Router上执行命令**display security-policy name policy-name**，可以观察到该安全策略规则。

```
<Huawei> display security-policy name policy_sec_1
Policy-name: policy_sec_1
Policy-ID: 4
AV: default
URLF: -
ACL: 0
Reference-Num: 1
```

在Router上执行**display firewall interzone zone-name1 zone-name2**，结果如下。

```
<Huawei> display firewall interzone Trust Untrust
interzone Trust Untrust
firewall disable
security-policy policy_sec_1
packet-filter default deny inbound
packet-filter default permit outbound
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
engine enable
#
profile type av name profile_av_pc
http-detect direction upload action block
ftp-detect direction upload action
block
#
profile type av name profile_av_server
http-detect direction upload action block
ftp-detect direction upload action block
```



```
exception application name Yahoo_WebMail action
block
security-policy policy_sec_1
  profile av profile_av_pc
security-policy policy_sec_2
  profile av profile_av_server
#
firewall zone Untrust
  priority 1
#
firewall zone DMZ
  priority 14
#
firewall zone Trust
  priority 13
#
firewall interzone Trust Untrust
  security-policy policy_sec_1
#
firewall interzone DMZ Trust
  security-policy policy_sec_2
#
firewall interzone DMZ Untrust
  security-policy policy_sec_2
#
interface GigabitEthernet1/0/0
  ip address 10.1.0.1 255.255.255.0
  zone DMZ
#
interface GigabitEthernet2/0/0
  ip address 10.2.0.1 255.255.255.0
  zone Trust
#
interface GigabitEthernet3/0/0
  ip address 1.1.1.1 255.255.255.0
  zone Untrust
#
return
```

8 本机防攻击配置

本机防攻击特性针对的是上送CPU的报文，主要用于保护设备的自身安全，保证设备在受到攻击时已有业务可以正常运转。

8.1 本机防攻击简介

本机防攻击可保护CPU，解决CPU因处理大量正常上送CPU的报文或者恶意攻击报文造成的业务中断问题。

8.2 本机防攻击配置注意事项

8.3 本机防攻击缺省配置

介绍设备的本机防攻击缺省配置，实际应用的配置可以基于缺省配置进行修改。

8.4 配置CPU防攻击

通过配置CPU防攻击，设备可以对上送CPU的报文进行限制和约束，使单位时间内上送CPU报文的数量限制在一定的范围之内，从而保护CPU的安全，保证CPU对业务的正常处理。

8.5 配置攻击溯源

通过配置攻击溯源，设备可以分析上送CPU的报文是否会对CPU造成攻击，对可能造成攻击的报文通过日志或告警提醒网络管理员，以便管理员采用一定的措施来保护设备。

8.6 配置用户级限速

8.7 维护本机防攻击

维护本机防攻击包括清除攻击源信息和清除上送CPU报文统计信息，可以帮助您定位攻击源或者确认攻击是否消除。

8.8 本机防攻击配置举例

介绍本机防攻击配置举例。配置示例中包括组网需求、配置思路等。

8.9 本机防攻击常见配置错误

介绍常见配置错误的案例，避免在配置阶段引入故障。

8.10 本机防攻击FAQ

8.1 本机防攻击简介

本机防攻击可保护CPU，解决CPU因处理大量正常上送CPU的报文或者恶意攻击报文造成的业务中断问题。

定义

在网络中，存在着大量针对CPU（Central Processing Unit）的恶意攻击报文以及需要正常上送CPU的各类报文。针对CPU的恶意攻击报文会导致CPU长时间繁忙的处理攻击报文，从而引发其他业务的断续甚至系统的中断；大量正常的报文也会导致CPU占用率过高，性能下降，从而影响正常的业务。

为了保护CPU，保证CPU对正常业务的处理和响应，设备提供了本机防攻击功能。本机防攻击针对的是上送CPU的报文，主要用于保护设备自身安全，保证已有业务在发生攻击时的正常运转，避免设备遭受攻击时各业务的相互影响。

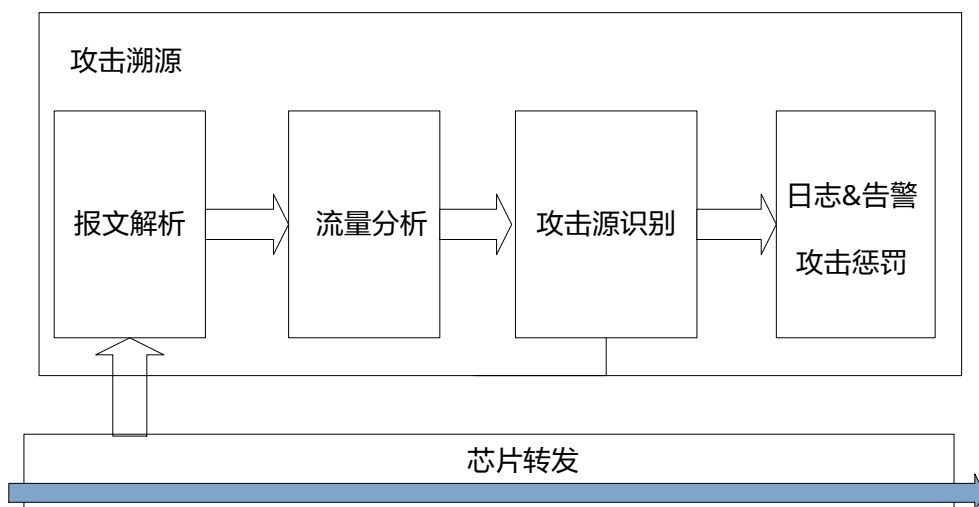
基本原理

本机防攻击包括CPU防攻击和攻击溯源两部分。

- CPU防攻击针对上送CPU的报文进行限制和约束，使单位时间内上送CPU报文的数量限制在一定的范围之内，从而保护CPU的安全，保证CPU对业务的正常处理。
 - a. 多级安全机制，保证设备的安全，实现了对设备的分级保护。
设备通过以下策略实现对设备的分级保护：
 - 第一级：通过黑名单来过滤上送CPU的非法报文。
 - 第二级：CPCAR（Control Plane Committed Access Rate）。对上送CPU的报文按照协议类型进行速率限制，保证每种协议上送CPU的报文不会过多。
 - 第三级：对上送CPU的报文，按照协议优先级进行调度，保证优先级高的协议先得到处理。
 - 第四级：对上送CPU的报文统一限速，对超过统一限速值的报文随机丢弃，保证整体上送CPU的报文不会过多，保护CPU安全。
 - b. 动态链路保护功能的CPU报文限速，是指当设备检测到SSH Session数据、Telnet Session数据、HTTP Session数据、FTP Session数据以及BGP Session数据建立时，会启动对此Session的动态链路保护功能，后续上送报文如匹配此Session特征信息，此类数据将会享受高速率上送的权利，由此保证了此Session相关业务的运行可靠性、稳定性。
- 攻击溯源针对DoS攻击进行防御。设备通过对上送CPU的报文进行分析统计，然后对统计的报文设置一定的阈值，将超过阈值的报文判定为攻击报文，再对这些攻击报文根据报文信息找出攻击源用户或者攻击源接口，最后通过日志、告警等方式提醒管理员以便管理员采用一定的措施来保护设备，或者直接丢弃攻击报文以对攻击源进行惩罚。

如图8-1所示，攻击溯源包括报文解析、流量分析、攻击源识别和发送日志告警通知管理员以及实施惩罚四个过程。

图 8-1 攻击溯源原理



通过图8-1所示的四个过程，找出攻击源，然后管理员通过ACL或配置黑名单的方式限制攻击源，以保护设备CPU。

8.2 本机防攻击配置注意事项

涉及网元

无需其他网元配合。

License 支持

本机防攻击是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

接口板上不支持应用防攻击策略。

8.3 本机防攻击缺省配置

介绍设备的本机防攻击缺省配置，实际应用的配置可以基于缺省配置进行修改。

本机防攻击的缺省配置如表8-1、表8-2所示。

表 8-1 CPU 防攻击缺省配置

参数	缺省值
防攻击策略	名称为 default 的防攻击策略
黑名单	没有黑名单
速率限制和协议优先级	防攻击策略对上送CPU的不同类型的报文，其缺省的速率限制和优先级，和 default 策略相同，可通过命令 display cpu-defend configuration 查看
统一限速值	1000pps
动态链路保护功能的限制速率	SSH、Telnet、SSHv6、Telnetv6、HTTP、FTP、IKE或BGP协议报文缺省的限制速率如下： • SSH：512pps • Telnet：512pps • SSHv6：512pps • Telnetv6：512pps • HTTP：512pps • FTP：1024pps • BGP：512pps • IKE：128pps 可以通过使用 application-apperceive 命令修改各协议的缺省值。

表 8-2 攻击溯源缺省配置

参数	缺省值
防攻击策略	名称为 default 的防攻击策略
攻击溯源功能	未使能
攻击溯源检查阈值	128pps
攻击溯源模式	基于源MAC地址、基于源IP地址和基于源接口+VLAN三种攻击溯源方式
攻击溯源防范的报文类型	ARP、DHCP、ICMP、IGMP、Telnet、TCP和TTL-expired报文
攻击溯源告警功能	未使能
攻击溯源告警阈值	128pps
攻击溯源的惩罚功能	未使能

8.4 配置 CPU 防攻击

通过配置CPU防攻击，设备可以对上送CPU的报文进行限制和约束，使单位时间内上送CPU报文的数量限制在一定的范围之内，从而保护CPU的安全，保证CPU对业务的正常处理。

前置任务

在配置CPU防攻击之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。
- 如果配置黑名单，请配置相应的ACL。

配置流程

在配置CPU防攻击任务中，必须首先创建防攻击策略，其余步骤是并列关系，无严格配置顺序，用户根据需要选择配置即可。防攻击策略在创建之后必须应用才能生效，但应用时机无严格限制。

8.4.1 创建防攻击策略

背景信息

用户需要先创建防攻击策略，然后在创建的防攻击策略中配置本机防攻击功能。

说明

防攻击策略对于从3G Cellular接口上送到主控板CPU的协议报文不生效。

操作步骤

步骤1 执行命令`system-view`，进入系统视图。

步骤2 执行命令`cpu-defend policy policy-name`，创建防攻击策略并进入防攻击策略视图。

设备最多支持19个防攻击策略。其中名称为**default**的策略为系统自动生成的缺省策略，**default**策略默认应用到所有单板，不允许删除，也不允许修改参数；其余18个允许用户创建、修改和删除。

步骤3 （可选）执行命令`description text`，配置防攻击策略的描述信息。

缺省情况下，防攻击策略没有配置描述信息。

----结束

8.4.2 配置黑名单

背景信息

通过创建黑名单，把符合特定特征的用户纳入到黑名单中，设备将直接丢弃黑名单用户上传的报文。设备支持通过ACL灵活设置黑名单。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy *policy-name***，进入防攻击策略视图。

步骤3 执行命令**blacklist *blacklist-id* acl *acl-number***，创建黑名单。

设备上最多可以配置8条黑名单。

黑名单应用的ACL可以是基本ACL、高级ACL或二层ACL。ACL的配置方法，请参见[5 ACL配置](#)。

缺省情况下，设备中没有配置黑名单。

----结束

8.4.3 配置动态调节 CPCAR 速率

背景信息

当系统受到攻击时，静态CPCAR速率限制功能不能及时的控制上送到CPU的报文速率，导致CPU占用率过高，从而严重影响CPU的运行状态。

动态调节CPCAR速率功能可以定时检测CPU占用率，当检测到当前系统的CPU占用率百分比超过设定的阈值时，将动态地调整协议报文的CPCAR大小到正常范围，从而减小攻击对CPU造成的影响。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy *policy-name***，进入防攻击策略视图。

步骤3 使能动态调节CPCAR速率功能，从以下两种方式中选择一种进行配置。

- **方式一：**

适用于不需要执行动态调节CPCAR速率的协议类型少于或等于8种的场景。

a. 执行命令**rate-adaption enable**，使能动态调节CPCAR速率功能。

缺省情况下，动态调节CPCAR速率功能处于未使能状态。

b. （可选）执行命令**rate-adaption exception packet-type *packet-type***，配置不执行动态调节CPCAR速率功能的协议类型。

缺省情况下，对所有协议类型执行动态调节CPCAR速率的功能。

- **方式二：**

适用于需要执行动态调节CPCAR速率的协议类型少于或等于8种的场景。

a. 执行命令**rate-adaption all-exception enable**，使能动态调节CPCAR速率功能，对所有协议类型不执行动态调节CPCAR速率的功能。

缺省情况下，动态调节CPCAR速率功能处于未使能状态。

b. 执行命令**rate-adaption include packet-type *packet-type***，配置执行动态调节CPCAR速率功能的协议类型。

缺省情况下，对所有协议类型不执行动态调节CPCAR速率的功能。

步骤4 执行命令**rate-adaption adjust-period** *period-value*，配置定时检测CPU占用率的时间周期。

缺省情况下，定时检测CPU占用率的时间周期为30秒。

步骤5 执行命令**rate-adaption cpu-usage threshold low** *low-value* **high** *high-value*，配置触发动态调节CPCAR功能的CPU负载阈值。

缺省情况下，触发动态调节CPCAR的CPU负载最低阈值为65%，最高阈值为85%。

步骤6 执行命令**rate-adaption adjust-step** *step-value*，配置动态调节CPCAR速率的幅度。

缺省情况下，动态调节CPCAR速率的幅度为20%。

----结束

8.4.4 配置速率限制

背景信息

设备可以通过对不同类型的报文设置不同的限制速率，也可以对报文设置为丢弃，从而减少上送CPU的报文数量，降低不同类型报文的相互影响，达到保护CPU的目的。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 配置速率限制。

- 执行命令**packet-type** *packet-type* **rate-limit** *rate-value*，配置对上送CPU的报文进行限速，并设置速率阈值。超过此速率限制的报文将会被丢弃。
- 执行命令**deny packet-type** *packet-type*，配置对上送CPU的报文进行丢弃。丢弃报文相当于将该类型报文的限速阈值设置为0。

缺省情况下，设备对上送CPU的报文按照**default**策略缺省的限速值进行限速。

----结束

8.4.5 配置协议优先级

背景信息

创建防攻击策略后，可以在防攻击策略中对上送CPU的报文按照协议优先级进行调度，保证优先级高的协议先得到处理。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**packet-type** *packet-type* **priority** *priority-level*，配置上送CPU报文的协议类型的优先级。

缺省情况下，使用**default**策略的缺省配置对上送CPU报文的协议类型区分优先级。

----结束

8.4.6 配置动态链路保护功能

背景信息

为了保证基于会话的应用层数据在攻击发生时可以正常运行，可以配置动态链路保护功能，应用层数据包括SSH Session数据、Telnet Session数据、SSHv6 Session数据、Telnetv6 Session数据、HTTP Session数据、FTP Session数据、IKE Session数据以及BGP Session数据。

动态链路保护功能限制速率在防攻击策略视图下进行配置，可以随防攻击策略应用在相应的接口板或者主控板上；而**cpu-defend application-apperceive**则是动态链路保护功能的开关。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy policy-name**，进入防攻击策略视图。

步骤3 执行命令**application-apperceive packet-type { ssh | telnet | sshv6 | telnetv6 | bgp | ftp | http | ike } rate-limit rate-value**，配置SSH、Telnet、SSHv6、Telnetv6、HTTP报文、BGP报文、FTP报文、IKE报文的动态链路保护功能的限制速率。

缺省情况下，SSH报文、Telnet报文、SSHv6报文、Telnetv6报文、HTTP报文、BGP报文的动态链路保护功能的限制速率是512pps，IKE报文的动态链路保护功能的限制速率是128pps，FTP报文的动态链路保护功能的限制速率是1024pps。

说明

如果用户没有配置**application-apperceive**的限制速率，那么SSH、Telnet、SSHv6、Telnetv6、HTTP、FTP、IKE、BGP协议报文使用**application-apperceive**命令缺省的限制速率上送。

配置FTP协议的动态链路保护功能后，对TFTP协议也生效。

配置指定协议类型为**sshv6**、**telnetv6**、**ike**的报文的动态链路保护功能只在主控板上生效。

步骤4 执行命令**quit**，进入系统视图。

步骤5 执行命令**cpu-defend application-apperceive [ssh | telnet | sshv6 | telnetv6 | bgp | ftp | http | ike] enable**，使能动态链路保护功能。

缺省情况下，对于SSH协议、Telnet协议、SSHv6协议、Telnetv6协议、BGP协议、FTP协议、IKE协议和HTTP协议，已使能动态链路保护功能。

----结束

8.4.7 配置统一限速

背景信息

创建防攻击策略后，可以在防攻击策略中配置对所有上送CPU的报文进行统一限速。设备对超过统一限速值的报文随机丢弃，保证整体上送CPU的报文不会过多，保护CPU安全。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy *policy-name***，进入防攻击策略视图。

步骤3 执行命令**rate-limit all-packets pps *pps-value***，配置对所有上送CPU的报文进行统一限速。

缺省情况下，上送CPU报文的统一限速值为1000pps。

----结束

8.4.8 应用防攻击策略

背景信息

创建防攻击策略之后，必须将策略在系统视图下应用，否则防攻击策略不会生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend-policy *policy-name***，应用防攻击策略。

----结束

8.4.9 检查 CPU 防攻击配置结果

操作步骤

- 执行命令**display cpu-defend policy [*policy-name*]**，查看防攻击策略信息。
- 执行命令**display cpu-defend statistics [*packet-type packet-type*]**，查看上送CPU报文的统计信息。
- 执行命令**display cpu-defend configuration [*packet-type packet-type*] { *all* | *sru* }**，查看设备对协议报文限速的配置信息。
- 执行命令**display cpu-defend rate-adaption statistics [*packet-type packet-type*]**，查看动态调节CPCAR后报文的速率统计信息。

----结束

8.5 配置攻击溯源

通过配置攻击溯源，设备可以分析上送CPU的报文是否会对CPU造成攻击，对可能造成攻击的报文通过日志或告警提醒网络管理员，以便管理员采用一定的措施来保护设备。

前置任务

在配置攻击溯源之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。

配置流程

在配置攻击溯源任务中，必须首先创建防攻击策略，其余步骤是并列关系，无严格配置顺序，用户根据需要进行配置即可。防攻击策略在创建之后必须应用才能生效，但应用时机无严格限制。

8.5.1 创建防攻击策略

背景信息

用户需要先创建防攻击策略，然后在创建的防攻击策略中配置本机防攻击功能。

说明

防攻击策略对于从3G Cellular接口上送到主控板CPU的协议报文不生效。

操作步骤

步骤1 执行命令`system-view`，进入系统视图。

步骤2 执行命令`cpu-defend policy policy-name`，创建防攻击策略并进入防攻击策略视图。

设备最多支持19个防攻击策略。其中名称为**default**的策略为系统自动生成的缺省策略，**default**策略默认应用到所有单板，不允许删除，也不允许修改参数；其余18个允许用户创建、修改和删除。

步骤3 （可选）执行命令`description text`，配置防攻击策略的描述信息。

缺省情况下，防攻击策略没有配置描述信息。

----结束

8.5.2 配置攻击溯源检查阈值

背景信息

网络上可能会出现大量攻击报文攻击设备的CPU。通过使能攻击溯源功能并配置攻击溯源检查阈值，设备可以分析上送CPU的报文是否会对CPU造成攻击。当可能的攻击源在单位时间内发送某种协议类型的报文超过检查阈值时，设备会将可能造成攻击的报文以日志方式通知网络管理员，以便网络管理员采取措施对攻击源进行防御部署。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**cpu-defend policy *policy-name***，进入防攻击策略视图。
- 步骤3** 执行命令**auto-defend enable**，使能攻击溯源功能。
缺省情况下，未使能攻击溯源功能。
- 步骤4** 执行命令**auto-defend threshold *threshold***，配置攻击溯源检查阈值。
缺省情况下，攻击溯源检查阈值为128pps。
- 结束

8.5.3 配置攻击溯源的溯源模式

背景信息

当攻击溯源启动后，设备将根据配置的溯源模式进行溯源。目前，设备支持三种溯源模式，分别适用于以下场景：

- 针对三层报文的攻击，则配置基于源IP地址进行溯源。
- 针对固定源MAC地址报文的攻击，则配置基于源MAC地址进行溯源。
- 针对变换源MAC地址报文的攻击，则配置基于接口和VLAN进行溯源。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**cpu-defend policy *policy-name***，进入防攻击策略视图。
- 步骤3** 执行命令**auto-defend enable**，使能攻击溯源功能。
缺省情况下，未使能攻击溯源功能。
- 步骤4** 执行命令**auto-defend trace-type { *source-ip* | *source-mac* | *source-portvlan* } ***，配置攻击溯源的溯源模式。
缺省情况下，攻击溯源的溯源模式为基于源MAC地址、基于源IP地址和基于源接口+VLAN。

说明

缺省情况下，三种攻击溯源模式都生效，如果只需要一种攻击溯源模式生效，一般是使用**undo auto-defend trace-type**命令来删除不需要的攻击溯源模式。如果不删除不需要的攻击溯源模式，溯源机制会将整个接口置Down，造成整个端口的业务不可用。

----结束

8.5.4 配置攻击溯源防范的报文类型

背景信息

当攻击发生时，由于设备同时对多种类型的报文进行溯源，网络管理员无法区分攻击报文的具体类型。通过灵活配置攻击溯源防范的报文类型，设备将针对所配置的报文类型进行溯源。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy *policy-name***，进入防攻击策略视图。

步骤3 执行命令**auto-defend enable**，使能攻击溯源功能。

缺省情况下，未使能攻击溯源功能。

步骤4 执行命令**auto-defend protocol { all | { arp | dhcp | icmp | igmp | tcp | telnet | ttl-expired | ospf } * }**，配置攻击溯源防范的报文类型。

缺省情况下，攻击溯源防范的报文类型为ARP、DHCP、ICMP、IGMP、TCP、Telnet、TTL-expired和OSPF。

----结束

8.5.5 配置攻击溯源事件上报功能

背景信息

当可能的攻击源在单位时间内发送某种协议类型的报文超过一定阈值时，如果希望设备能以事件上报的方式提醒网络管理员，以便管理员采取一定的措施来保护设备，则可以使能攻击溯源事件上报功能并配置攻击溯源事件上报阈值。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy *policy-name***，进入防攻击策略视图。

步骤3 执行命令**auto-defend enable**，使能攻击溯源功能。

缺省情况下，未使能攻击溯源功能。

步骤4 配置攻击溯源事件上报功能

1. 执行命令**auto-defend alarm enable**，使能攻击溯源事件上报功能。

缺省情况下，攻击溯源事件上报功能未使能。

2. 执行命令**auto-defend alarm threshold *threshold***，配置攻击溯源事件上报阈值。

缺省情况下，攻击溯源事件上报阈值为128pps。

----结束

8.5.6 配置攻击溯源惩罚功能

背景信息

配置对检测到的攻击源进行惩罚，设备将丢弃攻击源发送的攻击报文，从而避免攻击者继续攻击设备。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy *policy-name***，进入防攻击策略视图。

步骤3 执行命令**auto-defend enable**，使能攻击溯源功能。

缺省情况下，未使能攻击溯源功能。

步骤4 执行命令**auto-defend action deny [timer *time-length*]**，使能攻击溯源的惩罚功能。

缺省情况下，未使能攻击溯源的惩罚功能。

----结束

8.5.7 应用防攻击策略

背景信息

创建防攻击策略之后，必须将策略在系统视图下应用，否则防攻击策略不会生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend-policy *policy-name***，应用防攻击策略。

----结束

8.5.8 检查攻击溯源配置结果

操作步骤

- 执行命令**display auto-defend attack-source [detail]**，查看主控板的攻击源信息。
- 执行命令**display auto-defend configuration [cpu-defend policy *policy-name*]**，查看防攻击策略的攻击溯源配置信息。
- 执行命令**display cpu-defend policy [*policy-name*]**，查看防攻击策略的信息。

----结束

8.6 配置用户级限速

说明

V300R021C10SPC100及之后版本支持此功能。

8.6.1 使能用户级限速功能

背景信息

用户侧主机容易遭受病毒攻击，借此向网络中发送大量的协议报文，导致设备的CPU占用率过高，性能下降，从而影响正常的业务。管理员可以配置用户级限速功能，对用户的特定报文进行限速。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend host-car enable**，使能用户级限速功能。

缺省情况下，用户级限速的功能处于去使能状态。

----结束

8.6.2 配置用户级限速的限速值

背景信息

用户级限速是基于用户MAC地址识别用户，对用户的特定报文（ARP-Request）进行限速，包括有线用户和无线用户。管理员可以配置本功能对不同的用户设置不同的限速值。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend host-car enable**，使能用户级限速功能。

缺省情况下，用户级限速的功能处于去使能状态。

步骤3 执行命令**cpu-defend host-car [car-id car-id] pps pps-value**，配置限速桶的限速值。

缺省情况下，限速桶的限速值为10pps。

----结束

8.6.3 查看用户级限速丢弃的报文数

操作步骤

- 执行命令**display cpu-defend host-car [mac-address mac-address] statistics**，查看用户级限速丢弃的报文数。

----结束

8.7 维护本机防攻击

维护本机防攻击包括清除攻击源信息和清除上送CPU报文统计信息，可以帮助您定位攻击源或者确认攻击是否消除。

8.7.1 清除攻击溯源信息

背景信息

当需要对攻击溯源信息重新进行统计时，可以在用户视图下执行以下命令，清除之前的统计信息。

须知

清除攻击溯源信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

步骤1 执行命令**reset auto-defend attack-source**，清除主控板的攻击溯源信息。

----结束

8.7.2 清除上送 CPU 报文统计信息

背景信息

当需要对上送CPU的报文重新进行统计时，可以在用户视图下执行以下命令，清除之前的统计信息。

须知

清除上送CPU报文统计信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

步骤1 执行命令**reset cpu-defend statistics [packet-type packet-type]**，清除上送CPU报文统计信息。

----结束

8.8 本机防攻击配置举例

介绍本机防攻击配置举例。配置示例中包括组网需求、配置思路等。

8.8.1 配置本机防攻击示例

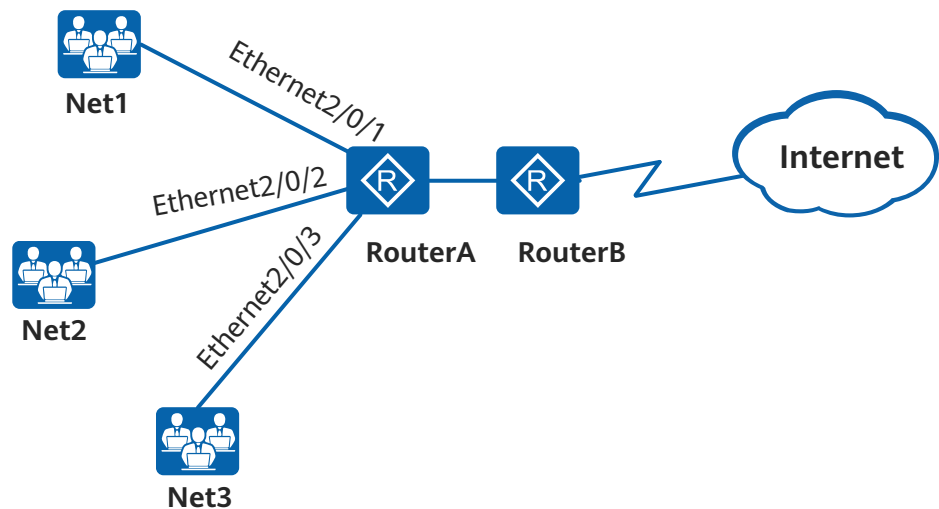
组网需求

如图8-2所示，位于不同局域网的用户通过RouterA访问Internet。为分析RouterA受攻击情况，需要配置攻击溯源检查功能记录攻击源信息。管理员发现存在以下现象：

- 通过攻击溯源检查功能分析可知，Net1网段中的某个用户经常会发生攻击行为。
- 攻击者发送大量的ARP Request报文，影响CPU的正常工作。
- 管理员需要以FTP方式上传文件到RouterA，此时需要建立管理员主机与RouterA之间的数据连接。
- 大多数局域网用户通过DHCP方式动态获取IP地址，但RouterA不优先处理上送CPU的DHCP Client报文。
- RouterA不应用Telnet Server功能，但经常收到大量的Telnet报文。

管理员希望通过在RouterA进行配置，以便解决上述问题。

图 8-2 配置本机防攻击组网图



配置思路

采用如下的思路配置本机防攻击：

1. 配置黑名单，将Net1网段中的攻击者列入黑名单，阻止其接入网络。
2. 配置ARP Request报文上送CPU的速率限制，使ARP Request报文限制在一个较小的速率范围内，减少对CPU处理正常业务的影响。
3. 配置FTP协议的动态链路保护功能，保证文件数据可以在管理员主机与RouterA之间正常传输。
4. 配置协议优先级，对DHCP Client报文设置较高的优先级，保证RouterA优先处理上送CPU的DHCP Client报文。
5. 关闭Router的Telnet服务器功能，使RouterA丢弃收到的Telnet报文。

操作步骤

步骤1 配置黑名单使用的ACL

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] acl number 4001
[RouterA-acl-L2-4001] rule 5 permit source-mac 00e0-fc01-0101
[RouterA-acl-L2-4001] quit
```

步骤2 创建防攻击策略

```
[RouterA] cpu-defend policy devicesafety
```

步骤3 配置攻击溯源检查功能

```
[RouterA-cpu-defend-policy-devicesafety] auto-defend enable  
[RouterA-cpu-defend-policy-devicesafety] auto-defend threshold 50
```

步骤4 配置黑名单

```
[RouterA-cpu-defend-policy-devicesafety] blacklist 1 acl 4001
```

步骤5 配置ARP Request报文上送CPU的速率限制

```
[RouterA-cpu-defend-policy-devicesafety] packet-type arp-request rate-limit 64
```

步骤6 配置FTP协议动态链路保护功能的速率限制值

```
[RouterA-cpu-defend-policy-devicesafety] application-apperceive packet-type ftp rate-limit 2000
```

步骤7 （可选）配置攻击溯源的溯源模式

```
[RouterA-cpu-defend-policy-devicesafety] auto-defend trace-type source-mac  
[RouterA-cpu-defend-policy-devicesafety] undo auto-defend trace-type source-ip source-portvlan
```

 说明

缺省情况下，三种攻击溯源模式都生效，如果只需要一种攻击溯源模式生效，一般是使用**undo auto-defend trace-type**命令来删除不需要的攻击溯源模式。如果不删除不需要的攻击溯源模式，溯源机制会将整个接口置Down，造成整个端口的业务不可用。

步骤8 配置DHCP Client报文的优先级

```
[RouterA-cpu-defend-policy-devicesafety] packet-type dhcp-client priority 3  
[RouterA-cpu-defend-policy-devicesafety] quit
```

步骤9 应用防攻击策略

使能FTP协议动态链路保护功能

```
[RouterA] cpu-defend application-apperceive ftp enable
```

应用防攻击策略到主控板

```
[RouterA] cpu-defend-policy devicesafety
```

步骤10 关闭telnet server功能。

```
[RouterA] undo telnet server enable
```

 说明

应用层联动不需要使能，只要关闭Router的Telnet服务器功能，Router会丢弃收到的Telnet报文。

步骤11 验证配置结果

查看配置的防攻击策略的信息。

```
[RouterA] display cpu-defend policy devicesafety  
Related slot : <0>  
BlackList Status :  
Slot<0> : Success  
Configuration :  
Blacklist 1 ACL number : 4001  
Packet-type arp-request rate-limit : 64(pps)  
Packet-type dhcp-client priority : 3  
Rate-limit all-packets : 2000(pps)(default)  
Application-apperceive packet-type ftp : 2000(pps)  
Application-apperceive packet-type tftp : 2000(pps)
```

查看主控板上配置的限速信息，显示结果表明，Telnet的应用层联动、对arp-request报文的限制速率和dhcp-client报文优先级的配置成功。

<Huawei> **display cpu-defend configuration sru**
Rate configurations on main board.

Packet-type	Status	Rate-limit(PPS)	Priority
8021X	Enabled	160	2
8021X-first	Enabled	50	2
arp-miss	Enabled	64	2
arp-reply	Enabled	128	2
arp-request	Enabled	64	2
bfd	Enabled	512	4
bgp	Enabled	512	3
bgp4plus	Enabled	512	3
capwap	Enabled	1536	1
dhcp-client	Enabled	256	3
.....			
telnet-server	Disabled	128	4
telnetv6-client	Disabled	128	4
telnetv6-server	Enabled	128	4
tth-expired	Enabled	256	1
udp-helper	Disabled	32	2
unknown-multicast	Enabled	256	1
unknown-packet	Enabled	256	1
voice	Enabled	256	4
vrrp	Disabled	1280	3
wapi	Enabled	1024	2
x25	Enabled	4096	1

Car all-packet (PPS) : 2500

配置攻击溯源检查功能后，对Net1网段中的攻击者进行溯源的日志信息显示，攻击溯源检查功能生效。

```
Dec 18 2010 09:55:50-05:13 device %01SECE/4/USER_ATTACK(l)[0]:User attack
occurred.(Slot=MPU, SourceAttackInterface=Ethernet2/0/1, OuterVlan/
InnerVlan=0/0, UserMacAddress=00e0-fc01-0101, AttackPackets=48 packets per
second)
```

查看上送到主控板的报文的统计信息，丢弃的报文表明设备对arp-request进行了速率限制。

<Huawei> **display cpu-defend statistics**

Packet Type	Pass Packets	Drop Packets
8021X	0	0
8021X-first	0	0
arp-miss	5	0
arp-reply	8090	0
arp-request	1446576	127773
bfd	0	0
bgp	0	0
bgp4plus	0	0
dhcp-client	879	0
dhcp-server	0	0
dhcpv6-reply	0	0
dhcpv6-request	0	0
.....		
udp-helper	0	0
unknown-multicast	0	0
unknown-packet	66146	0
voice	0	0
vrrp	0	0
wapi	0	0

```
x25          0          0
-----
```

----结束

配置文件

RouterA的配置文件

```
#
sysname RouterA
#
acl number 4001
 rule 5 permit source-mac 00e0-fc01-0101
#
cpu-defend policy devicesafety
 blacklist 1 acl 4001
 packet-type arp-request rate-limit 64
 packet-type dhcp-client priority 3
 application-apperceive packet-type ftp rate-limit 2000
 auto-defend enable
 auto-defend trace-type source-mac
 undo auto-defend trace-type source-ip source-
 portvlan
 auto-defend threshold 50
#
cpu-defend-policy devicesafety
#
return
```

8.9 本机防攻击常见配置错误

介绍常见配置错误的案例，避免在配置阶段引入故障。

8.9.1 攻击溯源功能不生效

故障现象

配置了攻击溯源功能后，攻击溯源功能不生效。

常见原因

本类故障的常见原因主要包括：

- 配置攻击溯源的防攻击策略没有运用在正确的主控板
- 攻击溯源的检测阈值过大造成设备不认为该报文为攻击报文

操作步骤

步骤1 确定被攻击对象

1. 执行命令**display cpu-usage**查看主控板的CPU占用率，以确定攻击报文是否攻击主控板。
2. 如果主控板受到攻击，则继续执行以下检查。

步骤2 确定配置攻击溯源的防攻击策略是否运用在被攻击的接口板或主控板

1. 在系统视图下执行命令**display this**，检查是否配置了**cpu-defend-policy**命令。

2. 或者执行命令**display auto-defend configuration**查看“Name”字段取值（防攻击策略名）和“Related slot”取值（应用的槽位号）。
3. 如果没有配置，则在系统视图下执行命令**cpu-defend-policy**进行配置，否则继续执行以下检查。

步骤3 检查攻击溯源检测阈值是否过大

执行命令**display auto-defend configuration**查看“auto-defend threshold”字段取值。如果攻击溯源的检查阈值较大，则在防攻击策略视图下执行命令**auto-defend threshold**命令减小攻击溯源的检查阈值。

----结束

8.9.2 黑名单功能不生效

故障现象

配置了黑名单功能后，黑名单功能不生效。

常见原因

本类故障的常见原因主要包括：

- 黑名单的规则与报文不匹配
- ACL资源不足造成黑名单应用失败

操作步骤

步骤1 执行命令**display cpu-defend policy policy-name**，查看防攻击策略相关信息。

步骤2 从防攻击策略显示信息中可查看到黑名单对应的ACL，然后执行命令**display acl acl-number**，检查ACL中的规则是否与业务需求一致。

步骤3 如果不一致，请在对应ACL视图下执行命令**rule**，修改规则，使之与业务需求一致。如果一致，可能是设备ACL资源不足造成黑名单应用失败。

----结束

8.10 本机防攻击 FAQ

8.10.1 本机防攻击中，如果黑名单应用的 ACL 组中的规则超过规格，超过部分如何处理

应用黑名单的过程中，ACL组中超过规格的规则将不再继续生效。

8.10.2 如何配置 CPCAR

CPCAR（Control Plane Committed Access Rate），控制面限速，如果需要配置CPCAR，请按照以下步骤，

- 使用**cpu-defend policy policy-name**命令，创建防攻击策略；

- 在防攻击策略视图下执行命令 **packet-type** *packet-type* **rate-limit** *rate-value*, 对上送CPU的报文进行限速，并设置速率阈值；
- 执行命令 **cpu-defend-policy** *policy-name*, 应用防攻击策略。

8.10.3 为什么配置了 CPCAR 限速值没有生效

CPCAR在防攻击策略视图下配置，只有当该防攻击策略应用到主控板时，配置才能生效。

9 攻击防范配置

攻击防范是一种重要的网络安全特性。通过配置攻击防范功能，设备能够检测出多种类型的网络攻击，并能采取相应的措施保护设备自身及其所连接的内部网络免受恶意攻击，保证内部网络及设备的正常运行。

9.1 攻击防范简介

介绍攻击防范的定义和作用。

9.2 攻击防范原理描述

介绍攻击防范的实现原理。

9.3 攻击防范应用场景

介绍攻击防范的应用场景。

9.4 攻击防范配置注意事项

介绍攻击防范的配置注意事项。

9.5 攻击防范缺省配置

介绍了攻击防范的缺省配置。

9.6 配置畸形报文攻击防范

畸形报文攻击防范主要防止没有IP载荷的泛洪攻击、IGMP空报文攻击、LAND攻击、Smurf攻击和TCP标志位非法攻击。

9.7 配置分片报文攻击防范

分片报文攻击主要包括分片数量巨大攻击、巨大offset攻击、重复分片攻击、Tear Drop攻击、Syndrop攻击、NewTear攻击、Bonk攻击、Nesta攻击、Rose攻击、Fawx攻击、Ping of Death攻击和Jolt攻击。

9.8 配置泛洪攻击防范

泛洪攻击防范主要防止TCP Syn泛洪攻击、UDP泛洪攻击和ICMP泛洪攻击。

9.9 清除攻击防范统计信息

9.10 攻击防范配置举例

介绍攻击防范的配置举例。配置示例中包括组网图需求、配置思路、操作步骤等。

9.1 攻击防范简介

介绍攻击防范的定义和作用。

定义

攻击防范是一种重要的网络安全特性。它通过分析上送CPU处理的报文的内容和行为，判断报文是否具有攻击特性，并配置对具有攻击特性的报文执行一定的防范措施。

攻击防范主要分为畸形报文攻击防范、分片报文攻击防范和泛洪攻击防范。

目的

目前，网络的攻击日益增多，而通信协议本身的缺陷以及网络部署问题，导致网络攻击造成的影响越来越大。特别是对网络设备的攻击，将会导致设备或者网络瘫痪等严重后果。

攻击防范针对上送CPU的不同类型攻击报文，采用丢弃或者限速的手段，以保障设备不受攻击的影响，使业务正常运行。

9.2 攻击防范原理描述

介绍攻击防范的实现原理。

9.2.1 畸形报文攻击防范

畸形报文攻击是通过向目标设备发送有缺陷的IP报文，使得目标设备在处理这样的IP报文时出错和崩溃，给目标设备带来损失。畸形报文攻击防范是指设备实时检测出畸形报文并予以丢弃，实现对本设备的保护。

畸形报文攻击主要分为以下几类：

没有 IP 载荷的泛洪

如果IP报文只有20字节的IP报文头，没有数据部分，就认为是没有IP载荷的报文。攻击者经常构造只有IP头部，没有携带任何高层数据的IP报文，目标设备在处理这些没有IP载荷的报文时会出错和崩溃，给设备带来损失。

启用畸形报文攻击防范后，设备在接收到没有载荷的IP报文时，直接将其丢弃。

IGMP 空报文

IGMP报文是20字节的IP头加上8字节的IGMP报文体，总长度小于28字节的IGMP报文称为IGMP空报文。设备在处理IGMP空报文时会出错和崩溃，给目标设备带来损失。

启用畸形报文攻击防范后，设备在接收到IGMP空报文时，直接将其丢弃。

LAND 攻击

LAND攻击是攻击者利用TCP连接三次握手机制中的缺陷，向目标主机发送一个源地址和目的地址均为目标主机、源端口和目的端口相同的SYN报文，目标主机接收到该报文后，将创建一个源地址和目的地址均为自己的TCP空连接，直至连接超时。在这种攻击方式下，目标主机将会创建大量无用的TCP空连接，耗费大量资源，直至设备瘫痪。

启用畸形报文攻击防范后，设备采用检测TCP SYN报文的源地址和目的地址的方法来避免LAND攻击。如果TCP SYN报文中的源地址和目的地址一致，则认为是畸形报文攻击，丢弃该报文。

Smurf 攻击

Smurf攻击是指攻击者向目标网络发送源地址为目标主机地址、目的地址为目标网络广播地址的ICMP请求报文，目标网络中的所有主机接收到该报文后，都会向目标主机发送ICMP响应报文，导致目标主机收到过多报文而消耗大量资源，甚至导致设备瘫痪或网络阻塞。

启用畸形报文攻击防范后，设备通过检测ICMP请求报文的目标地址是否是广播地址或子网广播地址来避免Smurf攻击。如果检测到此类报文，直接将其丢弃。

TCP 标志位非法攻击

TCP报文包含6个标志位：URG、ACK、PSH、RST、SYN、FIN，不同的系统对这些标志位组合的应答是不同的：

- 6个标志位全部为1，就是圣诞树攻击。设备在受到圣诞树攻击时，会造成系统崩溃。
- SYN和FIN同时为1，如果端口是关闭的，会使接收方应答一个RST | ACK消息；如果端口是打开的，会使接收方应答一个SYN | ACK消息，这可用于主机探测(主机在线或者下线)和端口探测（端口打开或者关闭）。
- 6个标志位全部为0，如果端口是关闭的，会使接收方应答一个RST | ACK消息，这可以用于探测主机；如果端口是开放的，Linux和UNIX系统不会应答，而Windows系统将回答RST | ACK消息，这可以探测操作系统类型（Windows系统，Linux和UNIX系统等）。

启用畸形报文攻击防范后，设备采用检查TCP的各个标志位避免TCP标志位非法攻击，如果符合下面条件之一，则将该TCP报文丢弃：

- 6个标志位全部为1；
- SYN和FIN位同时为1；
- 6个标志位全部为0。

9.2.2 分片报文攻击防范

分片报文攻击是通过向目标设备发送分片出错的报文，使得目标设备在处理分片错误的报文时崩溃、重启或消耗大量的CPU资源，给目标设备带来损失。分片报文攻击防范是指设备实时检测出分片报文并予以丢弃或者限速处理，实现对本设备的保护。

分片报文攻击主要分为以下几类：

分片数量巨大攻击

IP报文中的偏移量是以8字节为单位的。正常情况下，IP报文的头部有20个字节，IP报文的最大载荷为65515。对这些数据进行分片，分片个数最大可以达到8189片，对于超过8189的分片报文，设备在重组这些分片报文时会消耗大量的CPU资源。

启用分片报文攻击防范后，针对分片数量巨大攻击，如果同一报文的分片数目超过8189个，则设备认为是恶意报文，丢弃该报文的所有分片。

巨大 Offset 攻击

攻击者向目标设备发送一个Offset值超大的分片报文，从而导致目标设备分配巨大的内存空间来存放所有分片报文，消耗大量资源。

Offset字段的最大取值为65528，但是在正常情况下，Offset值不会超过8190（如果offset=8189*8，IP头部长度为20，最后一块报文最多只有3个字节IP载荷，所以正常Offset的最大值是8189），所以如果Offset值超过8190，则这种报文即为恶意攻击报文，设备直接丢弃。

启用分片报文攻击防范后，设备在收到分片报文时判断Offset*8是否大于65528，如果大于就当作恶意分片报文直接丢弃。

重复分片攻击

重复分片攻击就是把同样的分片报文多次向目标主机发送，存在两种情况：

- 多次发送的分片完全相同，这样会造成目标主机的CPU和内存使用不正常；
- 多次发送的分片报文不相同，但Offset相同，目标主机就会处于无法处理的状态：哪一个分片应该保留，哪一个分片应该丢弃，还是都丢弃。这样就会造成目标主机的CPU和内存使用不正常。

启用分片报文攻击防范后，对于重复分片类报文的攻击，设备实现对分片报文进行CAR（Committed Access Rate）限速，保留首片，丢弃其余所有相同的重复分片，保证不对CPU造成攻击。

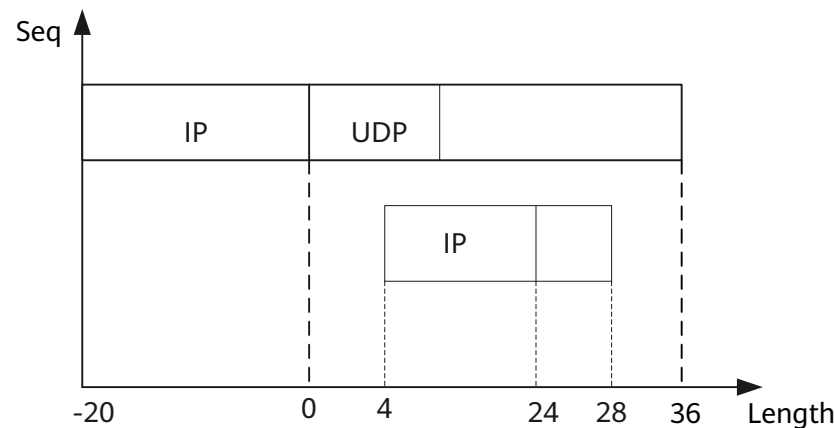
Tear Drop 攻击

Tear Drop攻击是最著名的IP分片攻击，原理是IP分片错误，第二片包含在第一片之中。即数据包中第二片IP包的偏移量小于第一片结束的位移，而且算上第二片IP包的Data，也未超过第一片的尾部。

如图9-1所示：

- 第一个分片IP载荷为36字节，总长度为56字节，protocol为UDP，UDP检验和为0（没有检验）；
- 第二片IP载荷为4字节，总长度为24字节，protocol为UDP，Offset=24（错误，正确应该为36）。

图 9-1 Tear Drop 攻击分片示意图



Tear Drop攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Tear Drop攻击，设备会直接丢弃所有分片报文。

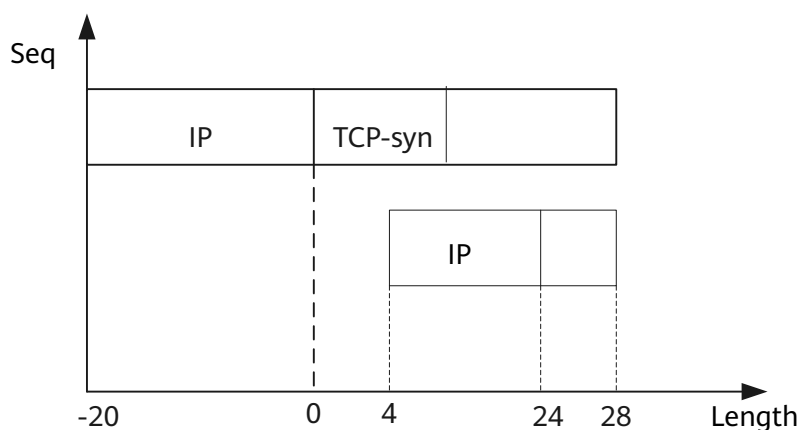
Syndrop 攻击

Syndrop攻击原理和Tear Drop原理一致，区别在于Syndrop攻击使用了TCP协议，Flag为SYN，而且带有载荷。

如图9-2所示：

- 第一片IP载荷为28字节，IP头部20字节；
- 第二片IP载荷为4字节，IP头部20字节，Offset=24（错误，正确应该是28）。

图 9-2 Syndrop 攻击分片示意图



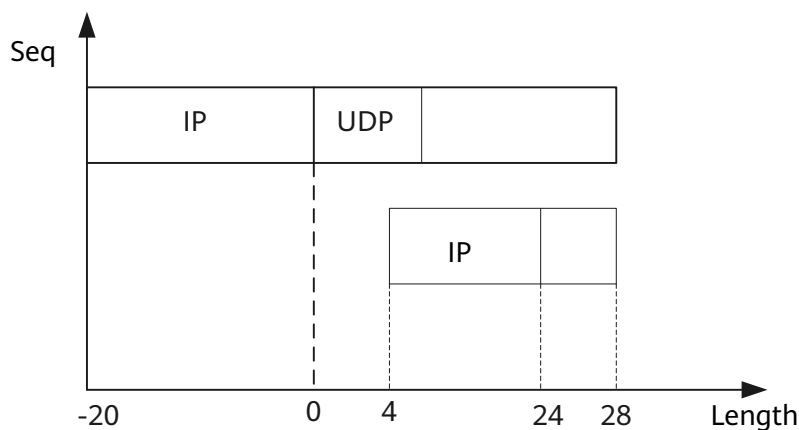
Syndrop攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Syndrop攻击，设备会直接丢弃所有分片报文。

NewTear 攻击

NewTear攻击是分片错误的攻击。如图9-3所示，protocol使用UDP。

- 第一片IP载荷28字节（包含UDP头部，UDP检验和为0）；
- 第二片IP载荷4字节，offset=24（错误，正确应该是28）。

图 9-3 NewTear 攻击分片示意图



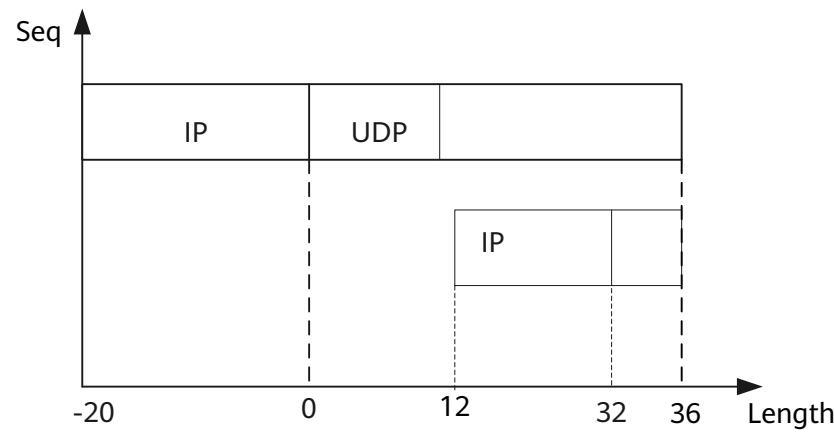
NewTear攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于NewTear攻击，设备会直接丢弃所有分片报文。

Bonk 攻击

Bonk攻击是分片错误的攻击。如图9-4所示，protocol使用UDP。

- 第一片IP载荷为36字节（包含UDP头部，UDP检验和为0）；
- 第二片IP载荷为4字节，offset=32（错误，正确应该是36）。

图 9-4 Bonk 攻击分片示意图



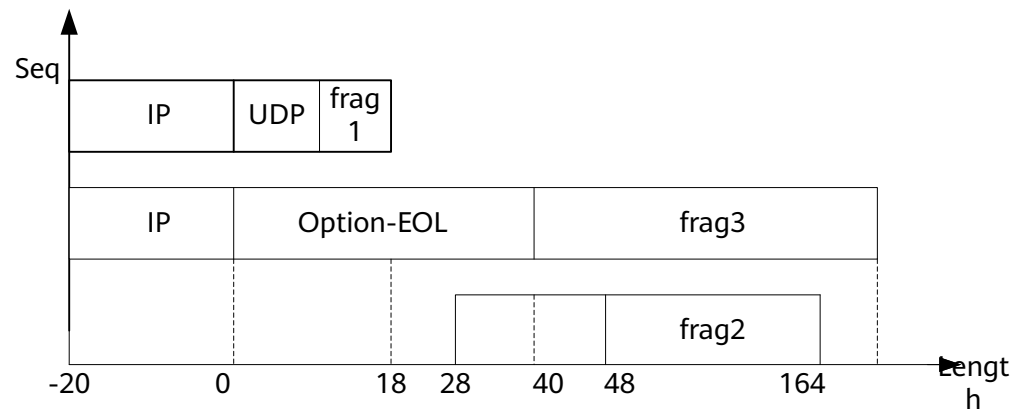
Bonk攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Bonk攻击，设备会直接丢弃所有分片报文。

Nesta 攻击

Nesta攻击是分片错误的攻击。如图9-5所示：

- 第一片IP载荷为18，protocol为UDP，检验和为0；
- 第二片offset为48，IP载荷为116字节；
- 第三片offset为0，more frag为1，也就是还有分片，40字节的IP option，都是EOL，IP载荷为224字节。

图 9-5 Nesta 攻击分片示意图



Nesta攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Nesta攻击，设备会直接丢弃所有分片报文。

Rose 攻击

IP protocol可以是UDP或TCP，可以选择。

如图9-6所示：

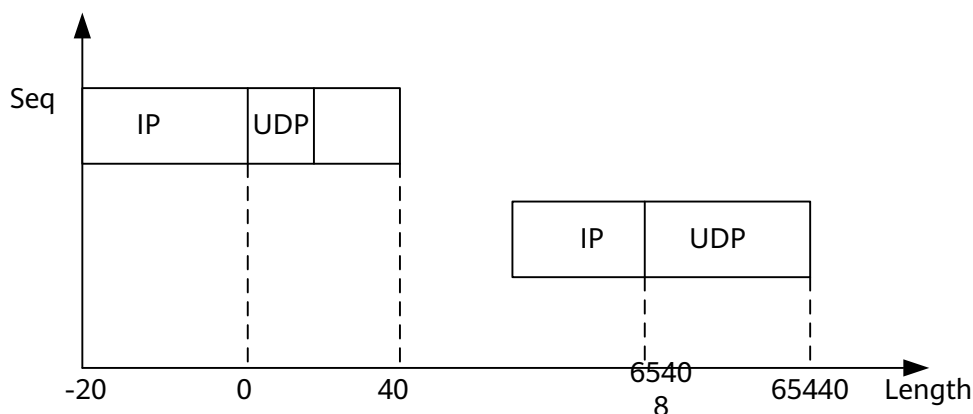
如果IP protocol是TCP：

- 第一片IP载荷为48字节（包含TCP头部），IP头部20字节；
- 第二片IP报文的载荷为32字节，但是offset=65408，more frag=0，即最后一片。

如果IP protocol是UDP：

- 第一片载荷长度40字节（包含UDP头部，UDP校验和为0），IP头部20字节；
- 第二片IP报文的载荷为32字节，但是offset = 65408，more frag = 0，即最后一片。

图 9-6 Rose 攻击分片示意图

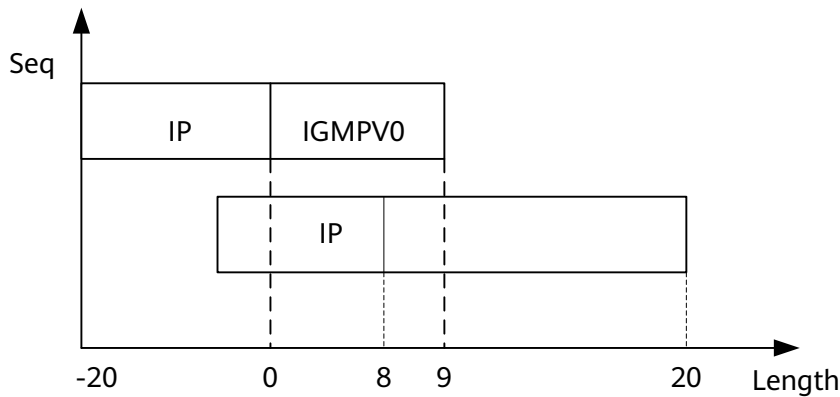


Rose攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Rose攻击，设备会直接丢弃所有分片报文。

Fawx 攻击

Fawx攻击是一种分片错误的IGMP报文。如图9-7，Fawx攻击的特征是：发送IGMP报文分片，一共两片，第一片9个字节，第二个分片offset = 8，载荷长度为16字节，没有结束分片。

图 9-7 Fawx 攻击分片示意图



Fawx攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Fawx攻击，设备会直接丢弃所有分片报文。

Ping of Death 攻击

Ping of Death攻击原理是攻击者发送一些尺寸较大（数据部分长度超过65507字节）的ICMP报文对设备进行攻击。设备在收到这样一个尺寸较大的ICMP报文后，如果处理不当，会造成协议栈崩溃。

启用分片报文攻击防范后，设备在收到这种攻击报文后，直接丢弃该报文。

Jolt 攻击

Jolt攻击是攻击者发送总长度大于65535字节的报文对设备进行攻击。Jolt攻击报文一共173个分片，每个分片报文的IP载荷为380字节，因此总长度为： $173 \times 380 + 20 = 65760$ ，远远超过65535。设备在收到这样的报文时，如果处理不当，会造成设备崩溃、死机或重启。

启用分片报文攻击防范后，设备在收到Jolt攻击报文后，直接丢弃该报文。

9.2.3 泛洪攻击防范

泛洪攻击是指攻击者在短时间内向目标设备发送大量的虚假报文，导致目标设备忙于应付无用报文，而无法为用户提供正常服务。

泛洪攻击防范是指设备实时检测出泛洪报文并予以丢弃或者限速处理，实现对本设备的保护。

泛洪攻击主要分为TCP SYN泛洪攻击、UDP泛洪攻击和ICMP泛洪攻击。

TCP SYN 泛洪攻击

TCP SYN攻击利用了TCP三次握手的漏洞。在TCP的3次握手期间，当接收端收到来自发送端的初始SYN报文时，向发送端返回一个SYN+ACK报文。接收端在等待发送端的最终ACK报文时，该连接一直处于半连接状态。如果接收端最终没有收到ACK报文包，则重新发送一个SYN+ACK到发送端。如果经过多次重试，发送端始终没有返回ACK报文，则接收端关闭会话并从内存中刷新会话，从传输第一个SYN+ACK到会话关闭大约需要30秒。

在这段时间内，攻击者可能将数十万个SYN报文发送到开放的端口，并且不回应接收端的SYN+ACK报文。接收端内存很快就会超过负荷，且无法再接受任何新的连接，并将现有的连接断开。

设备对TCP SYN攻击处理的方法是在使能了TCP SYN泛洪攻击防范后对TCP SYN报文进行速率限制，保证受到攻击时设备资源不被耗尽。

UDP 泛洪攻击

UDP泛洪攻击是指攻击者在短时间内向目标设备发送大量的UDP报文，导致目标设备负担过重而不能处理正常的业务。UDP泛洪攻击分为以下两类：

- Fraggle攻击
Fraggle攻击的原理是攻击者发送源地址为目标主机地址，目的地址为广播地址，目的端口号为7的UDP报文。如果该广播网络中有很多主机都起用了UDP响应请求服务，目的主机将收到很多回复报文，造成系统繁忙，达到攻击效果。
使能泛洪攻击防范功能后，设备默认UDP端口号为7的报文是攻击报文，直接将其丢弃。
- UDP诊断端口攻击
攻击者对UDP诊断端口（7-echo，13-daytime，19-Chargen等UDP端口）发送报文，如果同时发送的数据包数量很大，造成泛洪，可能影响网络设备的正常工作。
使能泛洪攻击防范功能后，设备将UDP端口为7、13和19的报文认为是攻击报文，直接丢弃。

ICMP 泛洪攻击

通常情况下，网络管理员会用Ping程序对网络进行监控和故障排除，大概过程如下：

1. 源设备向接收设备发出ICMP响应请求报文；
2. 接收设备接收到ICMP响应请求报文后，会向源设备回应一个ICMP应答报文。

如果攻击者向目标设备发送大量的ICMP响应请求报文，则目标设备会忙于处理这些请求，而无法继续处理其他的数据报文，造成对正常业务的冲击。

设备针对ICMP泛洪攻击进行CAR（Committed Access Rate）限速，保证CPU不被攻击，保证网络的正常运行。

9.3 攻击防范应用场景

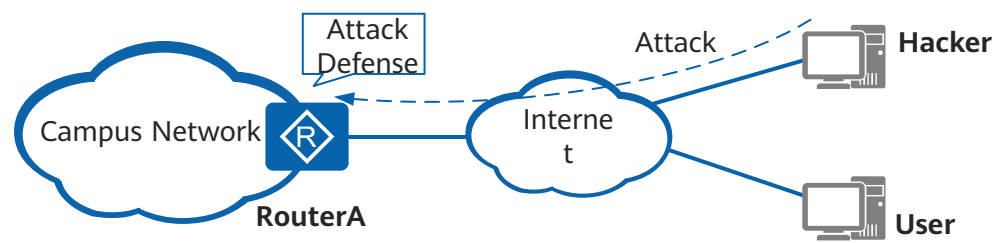
介绍攻击防范的应用场景。

如图9-8所示，RouterA经常会受到不同类型的网络攻击，这样会导致设备资源使用率过高，影响网络服务。为保障给用户提供安全的网络服务，在RouterA上部署攻击防范功能，主要防范的攻击类型包括：

- 畸形报文攻击防范，防止畸形报文攻击。
- 分片报文攻击防范，限制分片报文的速率，防止分片报文对CPU造成攻击，占用过多CPU和设备资源。
- 泛洪攻击防范，包括以下三种：
 - TCP SYN泛洪攻击防范，限制TCP SYN报文的速率，防止CPU处理TCP SYN报文占用过多资源；

- UDP泛洪攻击防范，对特定端口发送的UDP报文直接丢弃；
- ICMP泛洪攻击防范，限制ICMP泛洪攻击报文的上送速率，防止CPU处理ICMP泛洪攻击报文占用过多资源。

图 9-8 攻击防范应用组网图



9.4 攻击防范配置注意事项

介绍攻击防范的配置注意事项。

涉及网元

无需其他网元配合。

License 支持

攻击防范是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

9.5 攻击防范缺省配置

介绍了攻击防范的缺省配置。

攻击防范的缺省配置如表9-1所示。

表 9-1 攻击防范缺省配置

参数	缺省值
畸形报文攻击防范功能	已使能
分片报文攻击防范功能	已使能

参数	缺省值
分片报文发送速率	155000000bit/s
TCP Syn攻击防范功能	已使能
TCP Syn泛洪报文发送速率	155000000bit/s
UDP泛洪攻击防范功能	已使能
ICMP泛洪攻击防范功能	已使能
ICMP泛洪报文发送速率	155000000bit/s

9.6 配置畸形报文攻击防范

畸形报文攻击防范主要防止没有IP载荷的泛洪攻击、IGMP空报文攻击、LAND攻击、Smurf攻击和TCP标志位非法攻击。

背景信息

攻击者通过向目标设备发送畸形报文，使得目标设备在处理畸形报文时出错、崩溃，给目标设备带来损失，或者通过发送大量无用报文占用网络带宽等行为来造成攻击。

为了避免设备被畸形报文攻击的情况下瘫痪，保证正常的网络服务，可以配置畸形报文攻击防范。设备对畸形报文攻击防范的主要措施是判断是否是几种畸形报文攻击报文类型之一，若是，则直接丢弃畸形报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack abnormal enable**，使能畸形报文攻击防范功能。

缺省情况下，畸形报文攻击防范功能处于使能状态。

说明

在系统视图下，执行命令**anti-attack enable**可以使能所有的攻击防范功能（包括畸形报文攻击防范功能）。

----结束

检查配置结果

- 执行命令**display anti-attack statistics abnormal**，查看设备上畸形报文防攻击的统计数据。

9.7 配置分片报文攻击防范

分片报文攻击主要包括分片数量巨大攻击、巨大offset攻击、重复分片攻击、Tear Drop攻击、Syndrop攻击、NewTear攻击、Bonk攻击、Nesta攻击、Rose攻击、Fawx攻击、Ping of Death攻击和Jolt攻击。

背景信息

攻击者通过向目标设备发送分片出错的报文，使得目标设备在处理分片错误的报文时消耗大量的CPU资源，给目标设备带来损失。

为了避免设备被分片报文攻击的情况下瘫痪，保证正常的网络服务，可以配置分片报文攻击防范。对分片报文攻击防范的主要措施是进行速率限制，防止大量的分片报文造成CPU繁忙，保证CPU在造成攻击的情况下正常运行。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack fragment enable**，使能分片报文攻击防范功能。

缺省情况下，分片报文攻击防范功能处于使能状态。

说明

在系统视图下，执行命令**anti-attack enable**可以使能所有的攻击防范功能（包括分片报文攻击防范功能）。

步骤3 执行命令**anti-attack fragment car cir cir**，限制分片报文接收的速率。

缺省情况下，分片报文的接收速率为155000000bit/s。

----结束

检查配置结果

- 执行命令**display anti-attack statistics fragment**，查看设备上分片报文防攻击的统计数据。

9.8 配置泛洪攻击防范

泛洪攻击防范主要防止TCP SYN泛洪攻击、UDP泛洪攻击和ICMP泛洪攻击。

9.8.1 配置 TCP SYN 泛洪攻击防范

背景信息

攻击者向目标设备发送SYN报文，然后对于目标返回的SYN+ACK报文不作回应。目标设备如果没有收到攻击者的ACK回应，就会一直等待，形成半连接。攻击者利用这种方式，让目标设备上生成大量的半连接，迫使其大量资源浪费在这些半连接上。

为了避免TCP SYN泛洪攻击，可以在设备上配置TCP SYN泛洪攻击防范功能，通过限制TCP SYN报文的发送速率来防范TCP SYN泛洪攻击。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack tcp-syn enable**，使能TCP SYN泛洪攻击防范功能。

缺省情况下，TCP SYN泛洪攻击防范功能处于使能状态。

说明

在系统视图下，可以执行命令**anti-attack enable**使能所有的攻击防范功能（包括TCP SYN泛洪攻击防范功能）。

步骤3 执行命令**anti-attack tcp-syn car cir cir**，限制TCP SYN报文接收的速率。

缺省情况下，TCP SYN报文接收的速率为155000000bit/s。

----结束

9.8.2 配置 UDP 泛洪攻击防范

背景信息

如果攻击者在短时间内向特定目标发送特定目的端口号的UDP报文，会造成目标设备负担过重而不能处理正常的业务。为了避免UDP泛洪攻击，可以在设备上配置UDP泛洪攻击防范功能。

设备上配置UDP泛洪攻击防范功能，对于端口号为7、13和19的报文，直接丢弃。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack udp-flood enable**，使能UDP泛洪攻击防范功能。

缺省情况下，UDP泛洪攻击防范功能处于使能状态。

说明

在系统视图下，可以执行命令**anti-attack enable**使能所有的攻击防范功能（包括UDP泛洪攻击防范功能）。

----结束

9.8.3 配置 ICMP 泛洪攻击防范

背景信息

如果攻击者在短时间内向目标设备发送大量的ICMP响应请求报文，使目标设备忙于回复这些请求，会造成目标设备负担过重而不能处理正常的业务。为了避免ICMP泛洪攻击，可以在设备上配置ICMP泛洪攻击防范功能。

设备上配置ICMP泛洪攻击防范功能，通过限制ICMP报文的速率来防范ICMP泛洪攻击。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack icmp-flood enable**，使能ICMP泛洪攻击防范功能。

缺省情况下，ICMP泛洪攻击防范功能处于使能状态。

说明

在系统视图下，可以执行命令**anti-attack enable**使能所有的攻击防范功能（包括ICMP泛洪攻击防范功能）。

步骤3 执行命令**anti-attack icmp-flood car cir cir**，限制ICMP泛洪攻击报文接收的速率。

缺省情况下，ICMP泛洪攻击报文接收的速率为155000000bit/s。

----结束

9.8.4 检查泛洪攻击防范配置结果

操作步骤

- 执行**display anti-attack statistics [tcp-syn | udp-flood | icmp-flood]**命令，查看泛洪防攻击的统计数据。

----结束

9.9 清除攻击防范统计信息

背景信息

须知

清除信息后，以前的信息将无法恢复，务必仔细确认。

在确认需要清除攻击防范的统计信息时，请执行以下命令清除攻击防范的统计信息。

操作步骤

- 执行**reset anti-attack statistics [abnormal | fragment | tcp-syn | udp-flood | icmp-flood]**命令，清除攻击防范的报文统计信息。

----结束

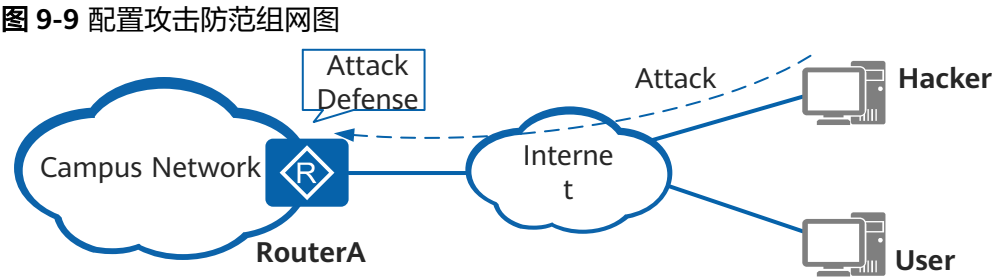
9.10 攻击防范配置举例

介绍攻击防范的配置举例。配置示例中包括组网图需求、配置思路、操作步骤等。

9.10.1 配置攻击防范示例

组网需求

如图9-9所示，如果Router会受到来自Internet网络不同类型的网络攻击，比如畸形报文攻击、分片报文攻击和泛洪攻击，将会造成RouterA瘫痪。为了预防这种情况，管理员希望通过在RouterA上部署各种攻击防范措施来为用户提供安全的网络环境，保障正常的网络服务。



配置思路

采用如下思路在RouterA上配置攻击防范：

- 1. 使能畸形报文攻击防范功能，避免畸形报文攻击。
- 2. 使能分片报文攻击防范功能，避免分片报文攻击。
- 3. 使能泛洪攻击防范功能，避免泛洪攻击。

操作步骤

步骤1 使能畸形报文攻击防范。

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] anti-attack abnormal enable
```

步骤2 使能分片报文攻击防范，并限制分片报文接收的速率为15000bit/s。

```
[RouterA] anti-attack fragment enable
[RouterA] anti-attack fragment car cir 15000
```

步骤3 使能泛洪攻击防范。

```
# 使能TCP SYN攻击防范，并限制TCP SYN报文接收的速率为15000bit/s。

[RouterA] anti-attack tcp-syn enable
[RouterA] anti-attack tcp-syn car cir 15000

# 使能UDP泛洪攻击防范，对特定端口发送的UDP报文直接丢弃。

[RouterA] anti-attack udp-flood enable

# 使能ICMP泛洪攻击防范，并限制ICMP泛洪报文接收的速率为15000bit/s。

[RouterA] anti-attack icmp-flood enable
[RouterA] anti-attack icmp-flood car cir 15000
```

步骤4 验证配置结果。

```
# 配置完成后，可以通过执行命令display anti-attack statistics查看报文攻击防范的统计数据。

[RouterA] display anti-attack statistics
Packets Statistic Information:
-----
AntiAtkType  TotalPacketNum      DropPacketNum      PassPacketNum
              (H)      (L)      (H)      (L)      (H)      (L)
-----
Abnormal      0        0        0        0        0        0
Fragment      0        0        0        0        0        0
Tcp-syn       0       34        0       28        0        6
```

Udp-flood	0	0	0	0	0	0
Icmp-flood	0	0	0	0	0	0

由显示信息可知，RouterA上产生了TCP SYN报文的丢弃计数，表明攻击防范功能已经生效。

----结束

配置文件

RouterA的配置文件

```
#
sysname RouterA
#
anti-attack fragment car cir 15000
anti-attack tcp-syn car cir 15000
anti-attack icmp-flood car cir 15000
#
return
```

10 流量抑制配置

流量抑制配置包括流量抑制的基础知识、配置方法、配置举例和常见配置错误。

10.1 流量抑制简介

介绍流量抑制的定义和作用。

10.2 流量抑制原理描述

介绍流量抑制的实现原理。

10.3 流量抑制应用场景

介绍流量抑制的应用场景。

10.4 流量抑制配置注意事项

介绍流量抑制的配置注意事项。

10.5 流量抑制缺省配置

介绍设备的流量抑制缺省值。

10.6 配置流量抑制

通过配置流量抑制，防范广播风暴，保障设备转发性能。

10.7 流量抑制配置举例

配置举例包括组网需求、配置思路、配置步骤和配置文件。

10.8 流量抑制常见配置错误

介绍了流量抑制常见配置错误，以及对其造成故障的处理思路。

10.9 流量抑制FAQ

10.1 流量抑制简介

介绍流量抑制的定义和作用。

定义

流量抑制是用于控制广播、组播以及未知单播报文，防止这三类报文引起广播风暴的安全技术。

流量抑制主要通过配置阈值来限制流量。

说明

未知单播报文是指目的MAC地址未被设备学习到的单播报文。

目的

当设备某个二层以太网接口收到广播、组播或未知单播报文时，如果根据报文的目的地MAC地址设备不能明确报文的出接口，设备会向同一VLAN内的其他二层以太网接口转发这些报文，这样可能导致广播风暴，降低设备转发性能。

引入流量抑制特性，可以控制这三类报文流量，防范广播风暴。

10.2 流量抑制原理描述

介绍流量抑制的实现原理。

10.2.1 流量抑制的基本原理

流量抑制特性按以下形式来限制广播、组播以及未知单播报文产生的广播风暴。

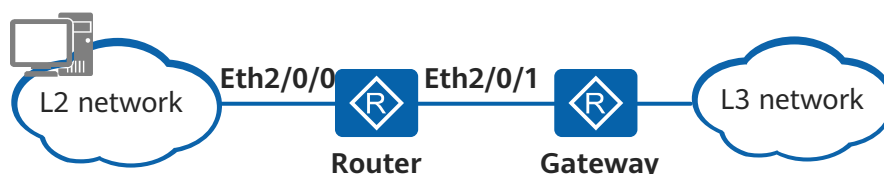
在接口视图下，入方向上，设备支持分别对三类报文按包速率和比特速率进行流量抑制。设备监控接口下的三类报文速率并和配置的阈值相比较，当入口流量超过配置的阈值时，设备会丢弃超额的流量。

10.3 流量抑制应用场景

介绍流量抑制的应用场景。

10.3.1 流量抑制的典型应用

图 10-1 流量抑制典型应用组网图



如图10-1所示，

- Router作为二层网络到路由器的衔接点，当需要限制二层网络转发的来自用户的广播、组播和未知单播报文时，可以通过在Router的二层以太网接口Eth2/0/0上配置流量抑制功能来实现。
- 在接口Eth2/0/0出方向上，可以采取阻塞广播、组播和未知单播报文的方式，保证二层网络内用户和其他网络设备的安全性。

10.4 流量抑制配置注意事项

介绍流量抑制的配置注意事项。

涉及网元

无需其他网元配合。

License 支持

流量抑制是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

10.5 流量抑制缺省配置

介绍设备的流量抑制缺省值。

流量抑制缺省值如表10-1所示。

表 10-1 流量抑制缺省值

参数	缺省值
接口的流量抑制	未使能
ICMP（Internet Control Message Protocol）报文流量抑制	未使能
ICMP报文接口的限速阈值	100pps

10.6 配置流量抑制

通过配置流量抑制，防范广播风暴，保障设备转发性能。

10.6.1 配置接口的流量抑制

背景信息

为了限制出入接口的广播、组播及未知单播报文的速率，防止广播风暴，可以在该接口上配置对应报文类型的流量抑制功能。

前置任务

- 在配置接口的流量抑制之前，需完成以下任务：
- 配置接口的链路层协议参数，使接口的链路协议状态为Up。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** （可选）执行命令**{ broadcast-suppression | multicast-suppression | unicast-suppression } cir cir-value**，配置基于全局的广播、组播、未知单播流量抑制。
- 步骤3** 执行命令**interface interface-type interface-number**，进入LAN侧以太网接口视图。
- 步骤4** 执行命令**{ broadcast-suppression | multicast-suppression | unicast-suppression } { cir cir-value | packets packets-per-second }**，配置基于接口的广播、组播、未知单播流量抑制。

 说明

仅AR720、AR730不支持此功能。

步骤4 仅8FE1GE单板上的LAN侧以太网接口支持此功能。

不同设备和单板支持的接口不同，所以支持的流量抑制模式也不同，以设备实际情况为准。

表 10-2 流量抑制模式支持情况说明

设备款型	cir模式的流量抑制	packets模式的流量抑制
8FE1GE	不支持	支持

- 步骤5** 执行命令 **flood-suppression cir cir-value**，配置基于接口的混合流量抑制。

 说明

仅AR720、AR730设备上的LAN侧以太网接口支持此功能，但无法限制未知单播报文。

----结束

10.6.2 配置 ICMP 报文流量抑制

应用环境

网络中经常存在ICMP报文攻击。如果设备有大量的ICMP请求广播报文攻击，这些报文都会上送CPU（Central Processing Unit）处理，使CPU占用率大大提高，导致其他业务功能异常。此时在设备上配置ICMP报文流量抑制功能，可以有效防范ICMP报文攻击。

配置ICMP报文流量抑制功能后，当接口每秒钟上送的ICMP报文超出配置的阈值时，设备会将ICMP报文丢弃。

说明

配置该功能后，会影响设备对PING报文的响应。

操作步骤

- 配置基于全局的ICMP报文限速。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**icmp rate-limit enable**，使能全局ICMP报文的限速功能。

缺省情况下，全局ICMP报文的限速功能不使能。
 - c. （可选）执行命令**icmp rate-limit threshold threshold-value**，配置基于全局的ICMP报文限速的阈值。

缺省情况下，全局的ICMP报文的限速阈值为100pps。
- 配置基于接口的ICMP报文限速。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**interface interface-type interface-number**，进入接口视图。
 - c. 执行命令**icmp rate-limit enable**，使能接口ICMP报文的限速功能。

缺省情况下，接口ICMP报文的限速功能未使能。
 - d. （可选）执行命令**icmp rate-limit threshold threshold-value**，配置基于接口的ICMP报文限速的阈值。

缺省情况下，接口的ICMP报文的限速阈值为100pps。

----结束

10.6.3 检查流量抑制配置结果

操作步骤

- 使用命令**display flow-suppression interface interface-type interface-number**查看流量抑制配置信息。

----结束

10.7 流量抑制配置举例

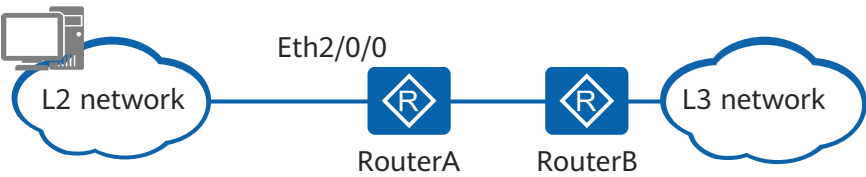
配置举例包括组网需求、配置思路、配置步骤和配置文件。

10.7.1 配置流量抑制示例

组网需求

如图10-2所示，RouterA作为二层网络到三层路由器RouterB的衔接点，当需要限制二层网络转发的来自用户的广播、组播或者未知单播报文时，可以通过在Ethernet 2/0/0接口上配置以包模式进行流量抑制来实现。

图 10-2 配置以包模式进行流量抑制组网图



配置思路

- 采用如下的思路：
- 直接在Ethernet 2/0/0接口视图下配置以包模式进行流量抑制的功能。

操作步骤

步骤1 进入接口视图

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] interface ethernet 2/0/0
```

步骤2 配置广播报文以包模式进行流量抑制

```
[RouterA-Ethernet2/0/0] broadcast-suppression packets 12600
```

步骤3 配置组播报文以包模式进行流量抑制

```
[RouterA-Ethernet2/0/0] multicast-suppression packets 25200
```

步骤4 配置未知单播报文以包模式进行流量抑制

```
[RouterA-Ethernet2/0/0] unicast-suppression packets 12600
[RouterA-Ethernet2/0/0] return
```

步骤5 验证配置结果

执行命令**display flow-suppression interface**查看Ethernet 2/0/0接口下的流量抑制配置情况。

```
[RouterA] display flow-suppression interface Ethernet 2/0/0
storm type      rate mode  set rate value
-----
unknown-unicast pps       pps: 12600(packet/s)
multicast       pps       pps: 25200(packet/s)
broadcast       pps       pps: 12600(packet/s)
flood
```

----结束

配置文件

RouterA的配置文件

```
#
sysname RouterA
#
interface Ethernet2/0/0
 unicast-suppression packets 12600
 multicast-suppression packets 25200
 broadcast-suppression packets 12600
```

```
#  
return
```

10.8 流量抑制常见配置错误

介绍了流量抑制常见配置错误，以及对其造成故障的处理思路。

10.8.1 广播流量抑制无效

故障现象

接口配置了广播流量抑制功能后，仍然出现了广播报文引起的广播风暴，导致正常流量中断。

常见原因

本类故障的常见原因主要包括：

- 接口下没有配置广播流量抑制或者配置的广播流量抑制值过大。
- 广播风暴报文在入接口没有丢弃。

说明

- 请保存以下步骤的执行结果，以便在故障无法解决时快速收集和反馈信息。
- 本文以广播流量抑制故障处理为例，组播和未知单播流量抑制的故障处理步骤与此类似。

操作步骤

步骤1 检查接口下的流量抑制配置。

用户视图下执行命令**display flow-suppression interface *interface-type interface-number***，查看输出信息中**broadcast**字段对应的**rate mode**和**set rate value**值，看其是否合适：

- 如果不合适，请在接口视图下执行命令**broadcast-suppression**修改广播流量抑制参数。
- 如果合适，执行步骤2。

步骤2 检查广播报文在接口入方向是否被丢弃。

有两种方法：

- 用户视图下执行命令**display interface *interface-type interface-number***，查看输出信息中**Input bandwidth utilization**是否在抑制前后有较大变化。正常情况下，在配置流量抑制之后，接口丢弃超过阈值限制的报文，接口带宽利用率会降低。如果没有变化或变化很小，请执行步骤3。
- 准备另外一个接口B，将要检查的接口A（即配置流量抑制的接口）和接口B加入相同VLAN，查看接口B的出方向流量是否为接口A上配置的抑制后的流量。如果不是，说明报文没有在接口A的入方向被丢弃。请执行步骤3。

步骤3 请收集如下信息，并联系技术支持人员。

- 上述步骤的执行结果。

- 设备的配置文件、日志信息、告警信息。

----结束

10.9 流量抑制 FAQ

10.9.1 为什么配置的流量抑制与实际抑制效果不一致

设备支持的流量抑制属于粒度限速：

- **cir**模式：粒度是32kbit/s，比如当流量抑制值设为10时，此配置按32kbit/s生效；当流量抑制值设为64时，此配置按64kbit/s生效，依次类推。
- **packets**模式：粒度是125pps，比如当流量抑制值设为10时，此配置按125pps生效；当流量抑制值设为126时，此配置按250pps生效，依次类推。

因此，当配置的流量抑制数值不是粒度的整数倍时，实际抑制效果与配置不一致，但只要在粒度范围内都是正确的。

11 ARP 安全配置

介绍ARP安全的原理和配置方法，并给出配置举例。

11.1 ARP安全简介

介绍ARP安全的定义和作用。

11.2 ARP安全原理描述

介绍ARP安全的实现原理。

11.3 ARP安全应用场景

介绍ARP安全的应用场景。

11.4 ARP安全配置注意事项

介绍ARP安全的配置注意事项。

11.5 ARP安全缺省配置

介绍设备的ARP安全缺省配置，实际应用的配置可以基于缺省配置进行修改。

11.6 配置ARP安全

介绍ARP安全详细的配置过程。

11.7 维护ARP安全

维护ARP安全包括监控ARP运行情况、清除ARP报文统计信息、清除ARP报文丢弃计数以及配置对潜在的ARP攻击行为发送日志和告警。

11.8 ARP安全配置举例

介绍ARP安全配置举例。配置示例中包括组网需求、配置思路、配置过程等。

11.9 ARP安全FAQ

11.1 ARP 安全简介

介绍ARP安全的定义和作用。

定义

ARP（Address Resolution Protocol）安全是针对ARP攻击的一种安全特性，它通过一系列对ARP表项学习和ARP报文处理的限制、检查等措施来保证网络设备的安全性。ARP安全特性不仅能够防范针对ARP协议的攻击，还可以防范网段扫描攻击等基于ARP协议的攻击。

目的

- ARP协议有简单、易用的优点，但是也因为其没有任何安全机制，容易被攻击者利用。在网络中，常见的ARP攻击方式主要包括：
- ARP泛洪攻击，也叫拒绝服务攻击DoS（Denial of Service），主要存在这样两种场景：
 - 设备处理ARP报文和维护ARP表项都需要消耗系统资源，同时为了满足ARP表项查询效率的要求，一般设备都会对ARP表项规模有规格限制。攻击者就利用这一点，通过伪造大量源IP地址变化的ARP报文，使得设备ARP表资源被无效的ARP条目耗尽，合法用户的ARP报文不能继续生成ARP条目，导致正常通信中断。
 - 攻击者利用工具扫描本网段主机或者进行跨网段扫描时，会向设备发送大量目标IP地址不能解析的IP报文，导致设备触发大量ARP Miss消息，生成并下发大量临时ARP表项，并广播大量ARP请求报文以对目标IP地址进行解析，从而造成CPU（Central Processing Unit）负荷过重。
 - ARP欺骗攻击，是指攻击者通过发送伪造的ARP报文，恶意修改设备或网络内其他用户主机的ARP表项，造成用户或网络的报文通信异常。

ARP攻击行为存在以下危害：

- 会造成网络连接不稳定，引发用户通信中断。
- 利用ARP欺骗截取用户报文，进而非法获取游戏、网银、文件服务等系统的帐号和口令，造成被攻击者重大利益损失。

为了避免上述ARP攻击行为造成的各种危害，ARP安全特性针对不同的攻击类型提供了多种解决方案，具体如表11-1和表11-2所示：

表 11-1 ARP 安全针对泛洪攻击的解决方案

防攻击功能	功能说明	部署设备
ARP报文限速	通过ARP报文限速功能，可以防止设备因处理大量ARP报文，导致CPU负荷过重而无法处理其他业务。	建议在网关设备上部署本功能
ARP Miss消息限速	通过ARP Miss消息限速功能，可以防止设备因收到大量目的IP不能解析的IP报文，触发大量ARP Miss消息，导致CPU负荷过重而无法处理其他业务。	建议在网关设备上部署本功能
ARP表项严格学习	使能ARP表项严格学习功能后，只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP。这可以防止设备收到大量ARP攻击报文时，ARP表被无效的ARP条目占满。	建议在网关设备上部署本功能

防攻击功能	功能说明	部署设备
ARP表项限制	使能ARP表项限制功能后，设备接口只能学习到设定的最大动态ARP表项数目。这可以防止当一个接口所接入的某一台用户主机发起ARP攻击时整个设备的ARP表资源都被耗尽。	建议在网关设备上部署本功能

表 11-2 ARP 安全针对欺骗攻击的解决方案

防攻击功能	功能说明	部署设备
ARP表项固化	使能ARP表项固化功能后，设备在第一次学习到ARP之后，不再允许用户更新此ARP表项或只能更新此ARP表项的部分信息，或者通过发送ARP请求报文的方式进行确认，以防止攻击者伪造ARP报文修改正常用户的ARP表项内容。 设备提供三种ARP表项固化模式：fixed-all模式、fixed-mac模式和send-ack模式。	建议在网关设备上部署本功能
动态ARP检测	使能动态ARP检测DAI（Dynamic ARP Inspection）功能后，当设备收到ARP报文时，将此ARP报文的源IP、源MAC、收到ARP报文的接口及VLAN信息和DHCP Snooping绑定表的信息进行比较，如果信息匹配，则认为是合法用户，允许此用户的ARP报文通过，否则认为是攻击，丢弃该ARP报文。 本功能仅适用于DHCP Snooping场景。	建议在接入设备上部署本功能
ARP防网关冲突	通过ARP防网关冲突功能，可以防止用户仿冒网关发送ARP报文，非法修改网络内其他用户的ARP表项。	建议在网关设备上部署本功能
发送免费ARP报文	使能发送免费ARP报文功能后，设备作为网关，主动向用户发送以自己IP地址为目标IP地址的ARP请求报文，定时更新用户ARP表项的网关MAC地址，防止用户的报文不能正常的转发到网关或者被恶意攻击者窃听。	建议在网关设备上部署本功能

防攻击功能	功能说明	部署设备
ARP报文内MAC地址一致性检查	通过ARP报文内MAC地址一致性检查功能，可以防止以太网数据帧首部中的源、目的MAC地址和ARP报文数据区中的源、目的MAC地址不一致的ARP欺骗攻击。	建议在网关设备上部署本功能
ARP报文合法性检查	使能ARP报文合法性检查功能后，设备会对以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址不一致的ARP报文进行过滤。	建议在网关设备或接入设备上部署本功能
ARP表项严格学习	使能ARP表项严格学习功能后，只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP。这可以防止设备因收到伪造的ARP报文，错误地更新ARP表项，导致合法用户的通信流量发生中断。	建议在网关设备上部署本功能

受益

- 可以有效降低用户为保证网络正常运行和网络信息安全而产生的维护成本。
- 可以为用户提供更安全的网络环境和更稳定的网络服务。

11.2 ARP 安全原理描述

介绍ARP安全的实现原理。

11.2.1 ARP 报文限速

如果设备对收到的大量ARP报文全部进行处理，可能导致CPU负荷过重而无法处理其他业务。因此，在处理之前，设备需要对ARP报文进行限速，以保护CPU资源。

设备提供了如下几类针对ARP报文的限速功能：

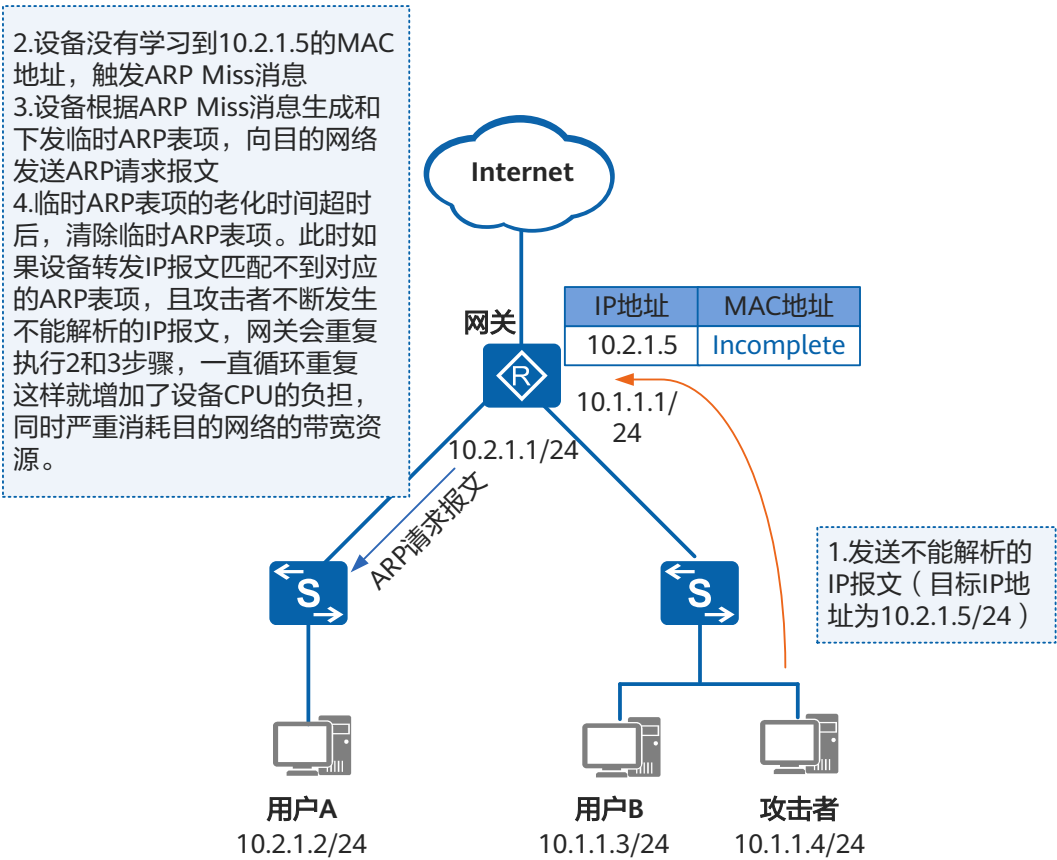
- 根据源MAC地址或源IP地址进行ARP报文限速
当设备检测到某一个用户在短时间内发送大量的ARP报文，可以针对该用户配置基于源MAC地址或源IP地址的ARP报文限速。在1秒时间内，如果该用户的ARP报文数目超过设定阈值（ARP报文限速值），则丢弃超出阈值部分的ARP报文。
 - 根据源MAC地址进行ARP报文限速：如果指定MAC地址，则针对指定源MAC地址的ARP报文根据限速值进行限速；如果不指定MAC地址，则针对每一个源MAC地址的ARP报文根据限速值进行限速。

- 根据源IP地址进行ARP报文限速：如果指定IP地址，则针对指定源IP地址的ARP报文根据限速值进行限速；如果不指定IP地址，则针对每一个源IP地址的ARP报文根据限速值进行限速。
- 针对Super VLAN的VLANIF接口下的ARP报文限速
当设备的VLANIF接口接收到触发ARP Miss消息的IP报文（关于ARP Miss消息的详细解释请参见[11.2.2 ARP Miss消息限速](#)）时，或者在设备的VLANIF接口上启用ARP代理功能之后，设备接收到目的IP符合代理条件且该IP对应的ARP条目不存在的ARP请求报文时，都会触发Super VLAN的VLANIF接口进行ARP学习。设备会将ARP请求报文在每个Sub VLAN下复制，如果该Super VLAN下配置了大量Sub VLAN，那么设备将产生大量的ARP请求报文。为了避免CPU因复制、发送大量ARP请求报文而负担过重，设备支持Super VLAN的VLANIF接口下的ARP报文限速功能，以对该场景下设备发送的ARP请求报文进行流量控制。
- 针对全局和接口的ARP报文限速
设备支持在全局和接口下配置ARP报文的限速值和限速时间，当同时在全局和接口下配置ARP报文的限速值和限速时间时，设备会先按照接口进行限速，再按照全局进行限速。
 - 针对全局的ARP报文限速：在设备出现ARP攻击时，限制全局处理的ARP报文数量。
 - 针对接口的ARP报文限速：在某个接口出现ARP攻击时，限制处理该接口收到的ARP报文数量，配置本功能可以保证不影响其他接口的ARP学习。

11.2.2 ARP Miss 消息限速

如果网络中有用户向设备发送大量目标IP地址不能解析的IP报文（即路由表中存在该IP报文的目的IP对应的路由表项，但设备上没有该路由表项中下一跳对应的ARP表项），将导致设备触发大量的ARP Miss消息。这种触发ARP Miss消息的IP报文（即ARP Miss报文）会被上送到主控板进行处理，设备会根据ARP Miss消息生成和下发大量临时ARP表项并向目的网络发送大量ARP请求报文，这样就增加了设备CPU的负担，同时严重消耗目的网络的带宽资源。如[图11-1](#)所示，攻击者向网关发送目的地址为10.2.1.5/24且不能解析的IP报文。

图 11-1 ARP Miss 攻击



为了避免这种IP报文攻击所带来的危害，设备提供了如下几类针对ARP Miss消息的限速功能：

- 根据源IP地址进行ARP Miss消息限速
当设备检测到某一源IP地址的IP报文在1秒内触发的ARP Miss消息数量超过了ARP Miss消息限速值，就认为此源IP地址存在攻击。
如果指定了IP地址，则针对指定源IP地址的ARP Miss消息根据限速值进行限速；如果不指定IP地址，则针对每一个IP地址的ARP Miss消息根据限速值进行限速。
- 针对全局的ARP Miss消息限速
设备支持对全局处理的ARP Miss消息数量，根据限速值进行限速。
- 通过设定临时ARP表项的老化时间控制ARP Miss消息的触发频率
当IP报文触发ARP Miss消息时，设备会根据ARP Miss消息生成临时ARP表项，并且向目的网段发送ARP请求报文。
 - 在临时ARP表项老化时间范围内：
 - 设备收到ARP应答报文前，匹配临时ARP表项的IP报文将被丢弃并且不会触发ARP Miss消息。
 - 设备收到ARP应答报文后，则生成正确的ARP表项来替换临时ARP表项。
 - 当老化时间超时后，设备会清除临时ARP表项。此时如果设备转发IP报文匹配不到对应的ARP表项，则会重新触发ARP Miss消息并生成临时ARP表项，如此循环重复。

当判断设备受到攻击时，可以增大临时ARP表项的老化时间，减小设备ARP Miss消息的触发频率，从而减小攻击对设备的影响。

11.2.3 ARP 表项严格学习

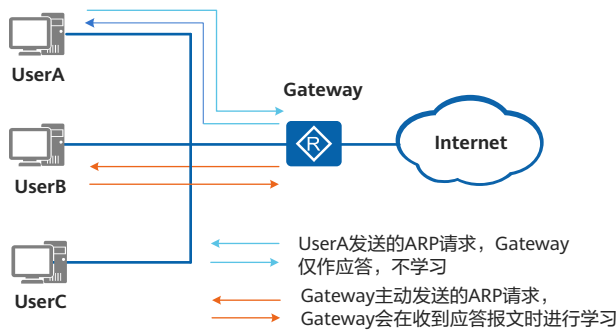
如果大量用户在同一时间段内向设备发送大量ARP报文，或者攻击者伪造正常用户的ARP报文发送给设备，则会造成下面的危害：

- 设备因处理大量ARP报文而导致CPU负荷过重，同时设备学习大量的ARP报文可能导致设备ARP表项资源被无效的ARP条目耗尽，造成合法用户的ARP报文不能继续生成ARP条目，进而导致用户无法正常通信。
- 伪造的ARP报文将错误地更新设备的ARP表项，导致用户无法正常通信。

为避免上述危害，可以在网关设备上部署ARP表项严格学习功能。

ARP表项严格学习是指只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP，这样，可以拒绝大部分的ARP报文攻击。

图 11-2 ARP 表项严格学习



如图11-2所示。通常情况下，当UserA向Gateway发送ARP请求报文后，Gateway会向UserA回应ARP应答报文，并且添加或更新UserA对应的ARP表项。当Gateway配置ARP表项严格学习功能以后：

- 对于Gateway收到UserA发送来的ARP请求报文，Gateway不添加也不更新UserA对应的ARP表项。如果该请求报文请求的是Gateway的MAC地址，那么Gateway会向UserA回应ARP应答报文。
- 如果Gateway向UserB发送ARP请求报文，待收到与该请求对应的ARP应答报文后，Gateway会添加或更新UserB对应的ARP表项。

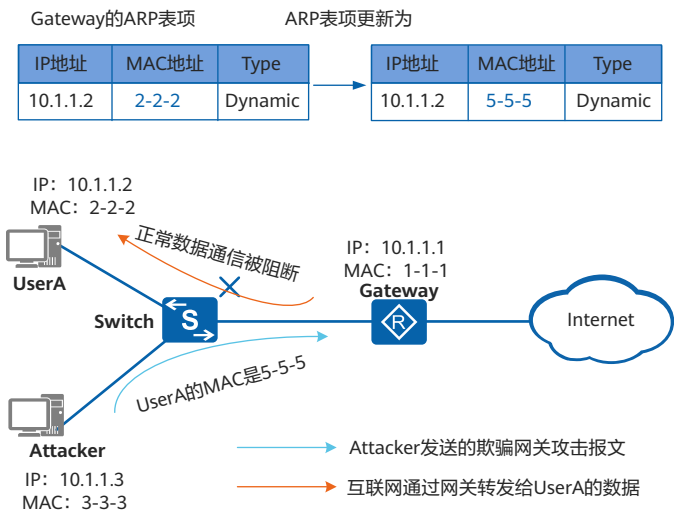
11.2.4 ARP 表项限制

ARP表项限制功能应用在网关设备上，可以限制设备的某个接口学习动态ARP表项的数目。默认状态下，接口可以学习的动态ARP表项数目规格与全局的ARP表项规格保持一致。当部署完ARP表项限制功能后，如果指定接口下的动态ARP表项达到了允许学习的最大数目，将不再允许该接口继续学习动态ARP表项，以保证当一个接口所接入的某一用户主机发起ARP攻击时不会导致整个设备的ARP表资源都被耗尽。

11.2.5 ARP 表项固化

如图11-3所示，Attacker仿冒UserA向Gateway发送伪造的ARP报文，导致Gateway的ARP表中记录了错误的UserA地址映射关系，造成UserA接收不到正常的报文。

图 11-3 欺骗网关攻击示意图



为了防御这种欺骗网关攻击，可以在网关设备上部署ARP表项固化功能。网关设备在第一次学习到ARP以后，不再允许用户更新此ARP表项或只能允许更新此ARP表项的部分信息，或者通过发送单播ARP请求报文的方式对更新ARP条目的报文进行合法性确认。

设备提供的三种ARP表项固化模式，如表11-3所示。

表 11-3 ARP 表项固化模式介绍

固化模式	功能
fixed-all模式	如果设备收到的ARP报文中的MAC地址、接口或VLAN信息和ARP表中的信息不匹配，则直接丢弃该ARP报文。此模式适用于用户MAC地址固定，并且用户接入位置相对固定的场景。
fixed-mac模式	如果设备收到的ARP报文中的MAC地址与ARP表中对应条目的MAC地址不匹配，则直接丢弃该ARP报文；如果匹配，但是收到报文的接口或VLAN信息与ARP表中对应条目不匹配，则可以更新对应ARP条目中的接口和VLAN信息。此模式适用于用户MAC地址固定，但用户接入位置频繁变动的场景。
send-ack模式	如果设备收到的ARP报文A涉及ARP表项MAC地址、接口或VLAN信息的修改，设备不会立即更新ARP表项，而是先向待更新的ARP表项现有MAC地址对应的用户发送一个单播的ARP请求报文进行确认。 - 如果在随后的3秒内设备收到ARP应答报文B，且当前ARP条目中的IP地址、MAC地址、接口和VLAN信息与ARP应答报文B的一致，则认为ARP报文A为攻击报文，不更新该ARP条目。 - 如果在随后的3秒内设备未收到ARP应答报文，或者收到ARP应答报文B与当前ARP条目中的IP地址、MAC地址、接口和VLAN信息不一致，设备会再向刚才收到的ARP报文A对应的源MAC发送一个单播ARP请求报文。 - 如果在随后的3秒内收到ARP应答报文C，且ARP报文A与ARP应答报文C的源IP地址、源MAC地址、接口和VLAN信息一致，则认为现有ARP条目已经无效且ARP报文A是可以更新该ARP条目的合法报文，并根据ARP报文A来更新该ARP条目。 - 如果在随后的3秒内未收到ARP应答报文，或者ARP报文A与收到的ARP应答报文C的源IP地址、源MAC地址、接口和VLAN信息不一致，则认为ARP报文A为攻击报文，设备会忽略收到的ARP报文A，ARP条目不会更新。 此模式适用于用户的MAC地址和接入位置均频繁变动的场景。

11.2.6 动态 ARP 检测

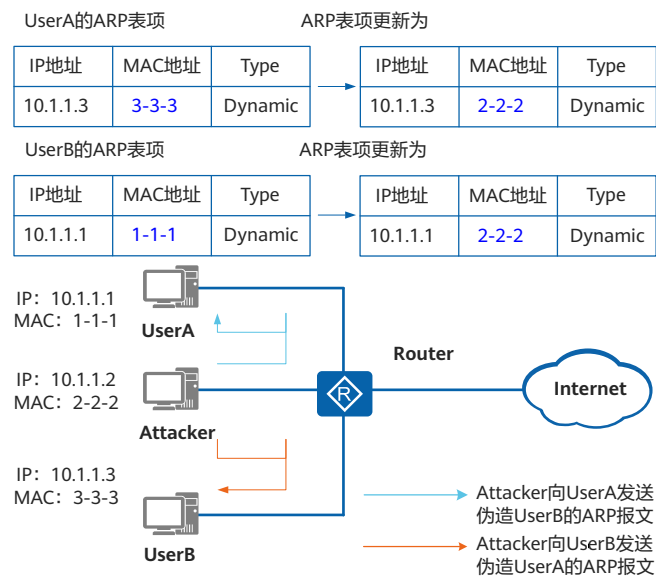
网络中针对ARP的攻击层出不穷，中间人攻击是常见的ARP欺骗攻击方式之一。

中间人攻击（Man-in-the-middle attack）是指攻击者与通讯的两端分别创建独立的联系，并交换其所收到的数据，使通讯的两端认为与对方直接对话，但事实上整个会话都被攻击者完全控制。在中间人攻击中，攻击者可以拦截通讯双方的通话并插入新的内容。

如图11-4所示，是中间人攻击的一个场景。攻击者主动向UserA发送伪造UserB的ARP报文，导致UserA的ARP表中记录了错误的UserB地址映射关系，攻击者可以轻易获取

到UserA原本要发往UserB的数据；同样，攻击者也可以轻易获取到UserB原本要发往UserA的数据。这样，UserA与UserB间的信息安全无法得到保障。

图 11-4 中间人攻击



为了防御中间人攻击，可以在Router上部署动态ARP检测DAI（Dynamic ARP Inspection）功能。

动态ARP检测是利用绑定表来防御中间人攻击的。当设备收到ARP报文时，将此ARP报文对应的源IP、源MAC、VLAN以及接口信息和绑定表的信息进行比较，如果信息匹配，说明发送该ARP报文的用户是合法用户，允许此用户的ARP报文通过，否则就认为是攻击，丢弃该ARP报文。

说明

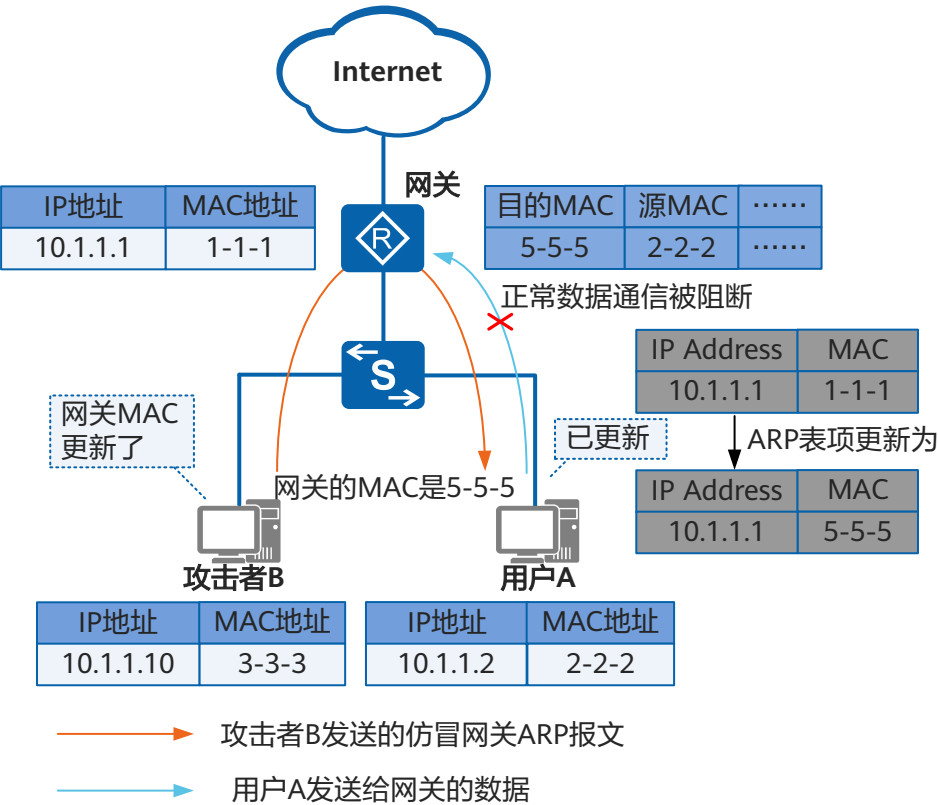
动态ARP检测功能仅适用于DHCP Snooping场景。设备使能DHCP Snooping功能后，当DHCP用户上线时，设备会自动生成DHCP Snooping绑定表；对于静态配置IP地址的用户，设备不会生成DHCP Snooping绑定表，所以需要手动添加静态绑定表。关于DHCP Snooping的详细介绍，请参见[DHCP Snooping的基本原理](#)中的描述。

当Router上部署动态ARP检测功能后，如果攻击者连接到Router并试图发送伪造的ARP报文，Router会根据绑定表检测到这种攻击行为，对该ARP报文进行丢弃处理。如果Router上同时使能了动态ARP检测丢弃报文告警功能，则当ARP报文因不匹配绑定表而被丢弃的数量超过了告警阈值时，Router会发出告警通知管理员。

11.2.7 ARP 防网关冲突

如图11-5所示，攻击者B将伪造网关的ARP报文发送给用户A，使用户A误以为攻击者即为网关。用户A的ARP表中会记录错误的网关地址映射关系，使得用户A跟网关的正常数据通信中断。

图 11-5 ARP 网关冲突



为了防范攻击者仿冒网关，可以在网关设备上使能ARP防网关冲突功能。当设备收到的ARP报文存在下列情况之一：

- ARP报文的源IP地址与报文入接口对应的VLANIF接口的IP地址相同
- ARP报文的源IP地址是入接口的虚拟IP地址，但ARP报文源MAC地址不是VRRP虚MAC

说明

一个VRRP备份组，被当作一个共享局域网内主机的缺省网关，即虚拟交换机。一个虚拟交换机拥有一个VRRP虚MAC，VRRP虚MAC根据虚拟交换机ID生成，格式为：00-00-5E-00-01-{VRID}{VRRP}。当虚拟交换机回应ARP请求时，使用的是VRRP虚MAC地址，而不是接口的真实MAC地址。

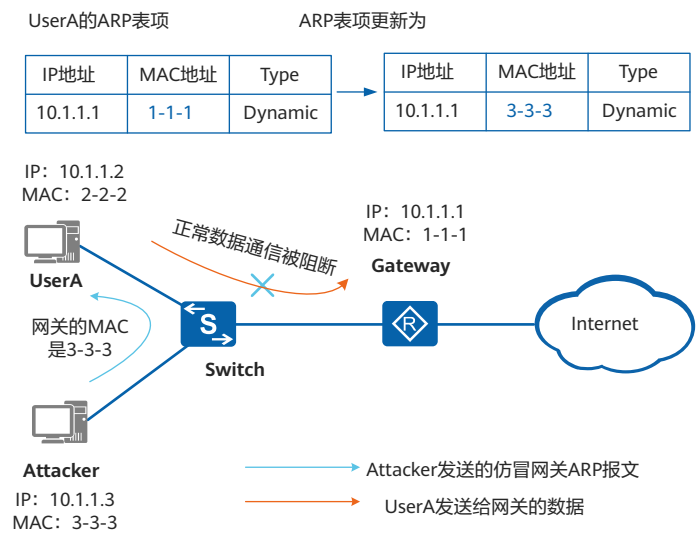
设备就认为该ARP报文是与网关地址冲突的ARP报文，设备将生成ARP防攻击表项，并在后续一段时间内丢弃该接口收到的同VLAN以及同源MAC地址的ARP报文，这样可以防止与网关地址冲突的ARP报文在VLAN内广播。

此时，还可以在设备上使能[发送免费ARP报文](#)功能，通过广播发送正确的免费ARP报文到所有用户，迅速将已经被攻击的用户记录的错误网关地址映射关系修改正确。

11.2.8 发送免费 ARP 报文

如[图11-6](#)所示，Attacker仿冒网关向UserA发送了伪造的ARP报文，导致UserA的ARP表中记录了错误的网关地址映射关系，从而正常的的数据不能被网关接收。

图 11-6 仿冒网关攻击



为了避免上述危害，可以在网关设备上部署发送免费ARP报文功能，定期更新用户的ARP表项，使得用户ARP表项中记录的是正确的网关MAC地址。

11.2.9 ARP 报文内 MAC 地址一致性检查

ARP报文内MAC地址一致性检查功能主要应用于网关设备上，可以防御以太网数据帧首部中的源/目的MAC地址和ARP报文中的源/目的MAC地址不同的ARP攻击。

部署本功能后，网关设备在进行ARP学习前将对ARP报文进行检查。如果以太网数据帧首部中的源/目的MAC地址和ARP报文中的源/目的MAC地址不同，则认为是攻击报文，将其丢弃；否则，继续进行ARP学习。

11.2.10 ARP 报文合法性检查

设备在收到ARP报文时，会对ARP报文的有效性进行检查，检查的项目包含但不限于：

- 检查报文的长度
- 以太网数据帧首部中的源MAC、目的MAC合法性检查
- ARP请求、回应类型检查
- MAC地址长度检查
- IP地址长度检查
- ARP帧格式是否为以太网帧类型检查

这些检查是用来判断ARP报文的格式跟ARP协议的规定是否一致。其中以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址不一致的ARP报文是协议允许的报文，但是在实际的应用中，该类报文很可能是攻击报文。

在接入设备或网关设备上使能ARP报文合法性检查功能后，设备会对收到的ARP报文进行以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址的一致性检查，如果两者不一致，则直接丢弃该ARP报文，否则允许该ARP报文通过。

11.2.11 DHCP 触发 ARP 学习

在DHCP用户场景下，当DHCP用户数目很多时，设备进行大规模ARP表项的学习和老化会对设备性能和网络环境形成冲击。

为了避免此问题，可以在网关设备上部署DHCP触发ARP学习功能。当DHCP服务器给用户分配了IP地址，网关设备会根据VLANIF接口上收到的DHCP ACK报文直接生成该用户的ARP表项。该功能生效的前提是使能DHCP Snooping功能。

网关设备上还可同时部署动态ARP检测功能，防止DHCP用户的ARP表项被伪造的ARP报文恶意修改。

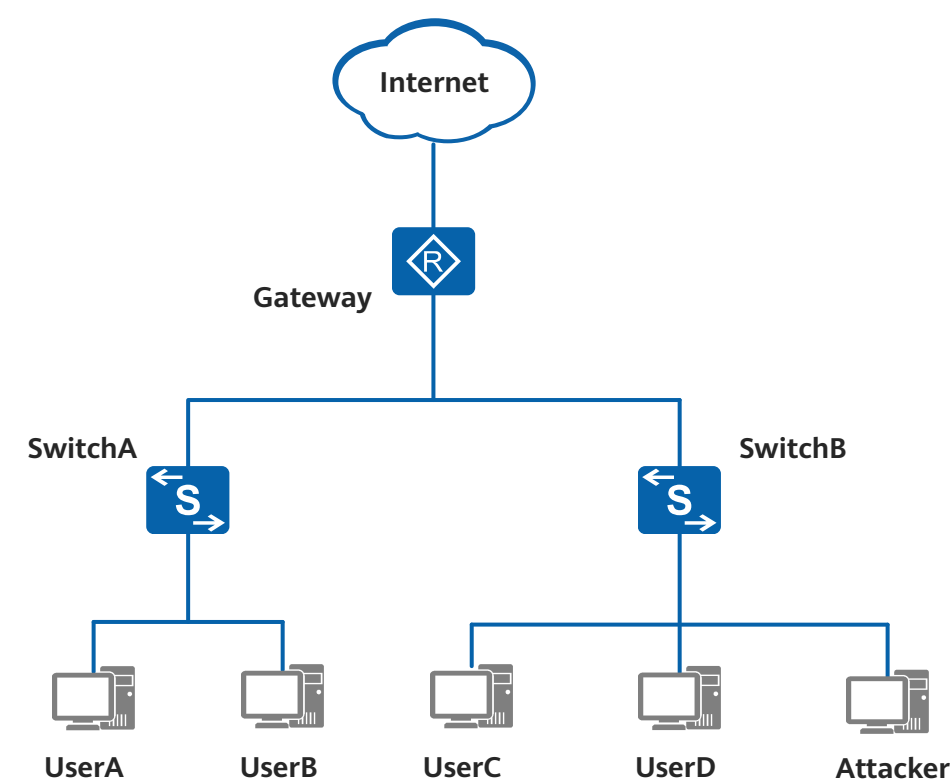
11.3 ARP 安全应用场景

介绍ARP安全的应用场景。

11.3.1 防 ARP 泛洪攻击

如图11-7所示，局域网中用户通过SwitchA和SwitchB接入连接到Gateway访问Internet。当网络中出现过多的ARP报文时，会导致网关设备CPU负载加重，影响设备正常处理用户的其它业务。另一方面，网络中过多的ARP报文会占用大量的网络带宽，引起网络堵塞，从而影响整个网络通信的正常运行。

图 11-7 防 ARP 泛洪攻击组网



为了避免上述危害，可以在网关设备上部署防ARP泛洪攻击功能，包括ARP报文限速功能、ARP Miss消息限速功能、ARP表项严格学习功能以及ARP表项限制功能。

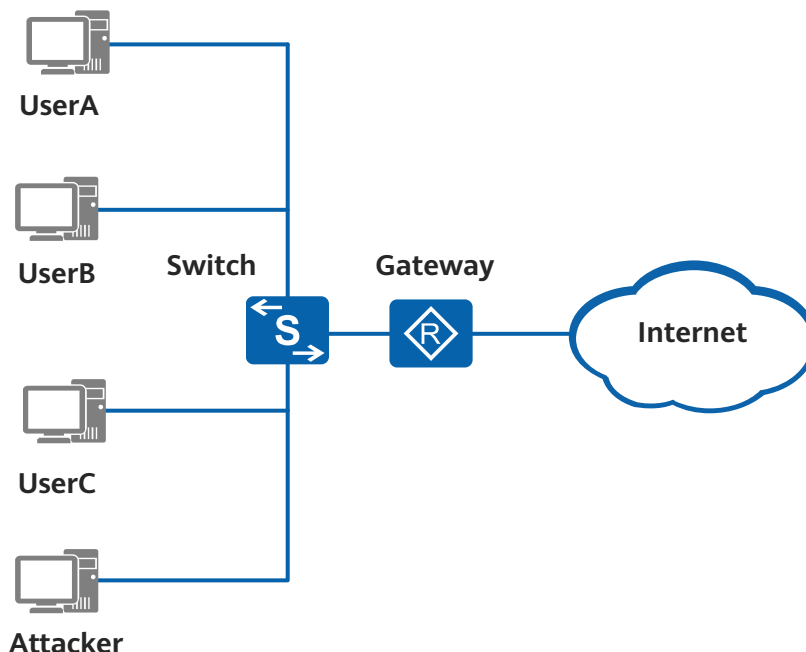
- 部署**ARP报文限速**功能后，Gateway会对收到的ARP报文进行数量统计，如果在一定时间内，ARP报文的数量超出了配置的阈值（ARP报文限速值），则丢弃超出阈值部分的ARP报文，这样可以防止设备因处理大量ARP报文造成CPU负荷过重。
- 部署**ARP Miss消息限速**功能后，Gateway会对ARP Miss消息进行数量统计，如果在一定时间内，ARP Miss消息的数量超出了配置的阈值（ARP Miss消息限速值），则超出部分的ARP Miss消息将被忽略，且Gateway会丢弃触发ARP Miss消息的IP报文，这样可以防止Gateway因处理大量目标IP地址不能解析的IP报文造成CPU负荷过重。
- 部署**ARP表项严格学习**功能后，Gateway仅仅学习自己发送的ARP请求报文的应答报文，并不学习其它设备主动向Gateway发送的ARP报文，这样可以防止Gateway因学习大量ARP报文而导致ARP表项资源被无效的ARP条目耗尽。
- 部署**ARP表项限制**功能后，Gateway会对各个接口学习动态ARP表项的数目进行限制。当指定接口下的动态ARP表项达到允许学习的最大数目后，将不允许新增动态ARP表项，这样可以防止一个接口所接入的某一用户主机发起ARP攻击而导致整个设备的ARP表资源都被耗尽。

11.3.2 防 ARP 欺骗攻击

如**图11-8**所示，局域网中UserA、UserB、UserC等用户通过Switch接入连接到Gateway访问Internet。

正常情况下，UserA、UserB、UserC上线之后，通过相互之间交互ARP报文，UserA、UserB、UserC和Gateway上都会创建相应的ARP表项。此时，如果有攻击者通过在广播域内发送伪造的ARP报文，篡改Gateway或者UserA、UserB、UserC上的ARP表项，攻击者可以轻而易举地窃取UserA、UserB、UserC的信息或者阻碍UserA、UserB、UserC正常访问网络。

图 11-8 防 ARP 欺骗攻击组网



为了避免上述危害，可以在网关设备上部署防ARP欺骗攻击功能，包括ARP表项固化功能、ARP表项严格学习功能、发送免费ARP报文等功能。

- 部署**ARP表项固化**功能后，Gateway在第一次学习到ARP之后，不再允许用户更新此ARP表项或只能更新此ARP表项的部分信息，或者通过发送单播ARP请求报文的方式对更新ARP条目的报文进行合法性确认，这样可以防止攻击者伪造ARP报文修改网关上其他用户的ARP表项。
- 部署**ARP表项严格学习**功能后，Gateway仅仅学习自己向UserA、UserB或UserC发送的ARP请求报文的应答报文，不学习攻击者主动向Gateway发送的ARP报文，并且不允许攻击者主动发送的ARP报文更新Gateway上现有的ARP条目，这样可以防止攻击者冒充其他用户修改网关上对应的ARP表项。
- 部署**发送免费ARP报文**功能后，Gateway主动向用户发送以自己IP地址为目标IP地址的ARP请求报文，定时更新用户ARP表项的网关MAC地址，这样可以防止用户的报文不能正常的转发到网关或者被恶意攻击者窃听。

11.4 ARP 安全配置注意事项

介绍ARP安全的配置注意事项。

涉及网元

无需其他网元配合。

License 支持

ARP安全是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

11.5 ARP 安全缺省配置

介绍设备的ARP安全缺省配置，实际应用的配置可以基于缺省配置进行修改。

ARP安全的缺省配置如表11-4所示。

表 11-4 ARP 安全缺省配置

参数	缺省值
ARP报文限速（根据源MAC地址）	对每一个源MAC地址的ARP报文速率限制为0，即不根据源MAC地址进行ARP报文限速
ARP报文限速（根据源IP地址）	设备允许1秒内最多只能有5个同一个源IP地址的ARP报文通过
ARP报文限速（针对全局和接口）	未使能
ARP报文的限速值、限速时间（针对全局和接口）	在1秒内设备最多允许100个ARP报文通过
ARP报文限速丢弃告警功能（针对全局和接口）	未使能
ARP报文限速丢弃告警阈值（针对全局和接口）	100
Super VLAN的VLANIF接口下ARP请求报文的广播发送限制速率	1000pps
ARP Miss消息限速（根据源IP地址）	设备允许每秒最多处理同一个源IP地址触发的5个ARP Miss消息
ARP Miss消息限速（针对全局）	未使能
ARP Miss消息的限速值、限速时间（针对全局）	在1秒内设备最多允许处理100个ARP Miss消息
ARP Miss消息限速丢弃告警功能（针对全局）	未使能

参数	缺省值
ARP Miss消息限速丢弃告警阈值（针对全局）	100
临时ARP表项的老化时间	1秒
ARP表项严格学习功能	未使能
基于接口的ARP表项限制	设备接口能学到的最大动态ARP表项数目是该接口下能配置的最大值
ARP表项固化功能	未使能
动态ARP检测功能	未使能
ARP防网关冲突防攻击功能	未使能
发送ARP免费报文功能	未使能
发送免费ARP报文的时间间隔	90秒
ARP报文内MAC地址一致性检查功能	未使能
ARP报文合法性检查功能	未使能
DHCP触发ARP学习功能	未使能

11.6 配置 ARP 安全

介绍ARP安全详细的配置过程。

11.6.1 配置防 ARP 泛洪攻击

通过配置防ARP泛洪攻击功能，可以避免ARP泛洪攻击带来的ARP表项资源被无效ARP条目耗尽、CPU负荷过重造成用户无法正常通信等危害。

前置任务

在配置防ARP泛洪攻击之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。

配置流程

在配置防ARP泛洪攻击任务中，各配置步骤均是并列关系，无严格配置顺序，用户根据需要进行选择配置即可。

说明

当针对全局、接口的ARP报文限速以及根据源MAC地址、源IP地址进行ARP报文限速中的多个限速功能同时配置时，设备对同时满足这些限速条件的ARP报文以其中最小的限速值进行限速。

当针对全局的ARP Miss消息限速以及根据源IP地址进行ARP Miss消息限速中的多个限速功能同时配置时，设备对同时满足这些限速条件的ARP Miss消息以其中最小的限速值进行限速。

11.6.1.1 配置 ARP 报文限速（根据源 MAC 地址）

背景信息

设备处理大量源MAC地址相对固定的ARP报文会造成CPU繁忙，并且如果ARP报文的源IP地址同时不断变化，还会导致设备的ARP表资源被耗尽。

为了避免此问题，可以在网关设备上配置设备根据源MAC地址进行ARP报文限速。设备会对上送CPU的ARP报文根据源MAC地址进行统计，如果在1秒内收到的同一个源MAC地址的ARP报文超过设定阈值（ARP报文限速值），设备则丢弃超出阈值部分的ARP报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置根据源MAC地址进行ARP报文限速

- 执行命令**arp speed-limit source-mac maximum *maximum***，配置根据任意源MAC地址进行ARP报文限速的限速值。
- 执行命令**arp speed-limit source-mac *mac-address* maximum *maximum***，配置对指定MAC地址用户的ARP报文进行限速的限速值。

两种配置同时存在的情况下，当ARP报文源MAC地址匹配限速指定的MAC地址时，对该源MAC地址的ARP报文限速值为后一步骤中配置的`maximum`值；否则为前一步骤中配置的`maximum`值。

缺省情况下，设备对每一个源MAC地址的ARP报文速率限制为0，即不根据源MAC地址进行ARP报文限速。

----结束

11.6.1.2 配置 ARP 报文限速（根据源 IP 地址）

背景信息

设备处理大量源IP地址相对固定的ARP报文（例如同一个源IP地址的ARP报文对应的MAC地址或出接口信息不断发生跳变），会造成CPU繁忙，影响到正常业务的处理。

为了避免此问题，可以在网关设备上配置设备根据源IP地址进行ARP报文限速。设备会对上送CPU的ARP报文根据源IP地址进行统计，如果在1秒内收到的同一个源IP地址的ARP报文超过设定阈值（ARP报文限速值），设备则丢弃超出阈值部分的ARP报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置根据源IP地址进行ARP报文限速

- 执行命令**arp speed-limit source-ip maximum *maximum***，配置根据任意源IP地址进行ARP报文限速的限速值。
- 执行命令**arp speed-limit source-ip *ip-address* maximum *maximum***，配置对指定IP地址用户的ARP报文进行限速的限速值。

两种配置同时存在的条件下，当ARP报文源IP地址匹配限速指定的IP地址时，对该源IP地址的ARP报文限速值为后一步骤中配置的`maximum`值；否则为前一步骤中配置的`maximum`值。

缺省情况下，设备允许1秒内最多只能有同一个源IP地址的5个ARP报文通过。

----结束

11.6.1.3 配置 ARP 报文限速（针对全局和接口）

背景信息

如果设备对收到的大量ARP报文全部进行处理，可能导致CPU负荷过重而无法处理其他业务。因此，在处理之前，设备需要对ARP报文进行限速，以保护CPU资源。

使能ARP报文限速功能后，可以在全局或接口下配置ARP报文的限速值和限速时间。在ARP报文限速时间内，如果收到的ARP报文数目超过ARP报文限速值，设备会丢弃超出限速值的ARP报文。

- 针对全局的ARP报文限速：在设备出现ARP攻击时，限制全局处理的ARP报文数量。
- 针对接口的ARP报文限速：在某个接口出现ARP攻击时，限制处理该接口收到的ARP报文数量，配置本功能可以保证不影响其他接口的ARP学习。

当同时在全局和接口下配置ARP报文的限速值和限速时间时，设备会先按照接口进行限速，再按照全局进行限速。

当设备丢弃的ARP报文数量较多时，如果希望设备能够以告警的方式提醒网络管理员，则可以使能ARP报文限速丢弃告警功能。当丢弃的ARP报文数超过告警阈值时，设备将产生告警。

说明

如果配置了ARP报文限速丢弃告警功能，则需使用命令`arp anti-attack log-trap-timer time`调整设备发送告警的时间间隔。

建议在网关设备上进行如下配置。

操作步骤

步骤1 执行命令`system-view`，进入系统视图。

步骤2 （可选）执行命令`interface interface-type interface-number`，进入接口视图。

说明

在系统视图下配置ARP报文限速功能无需执行此步骤。

步骤3 执行命令`arp anti-attack rate-limit enable`，使能ARP报文限速功能。

缺省情况下，未使能ARP报文限速功能。

步骤4 执行命令`arp anti-attack rate-limit packet-number [ interval-value ]`，配置ARP报文的限速值、限速时间。

缺省情况下，在1秒内设备最多允许100个ARP报文通过。

步骤5 （可选）执行命令**arp anti-attack rate-limit alarm enable**，使能ARP报文限速丢弃告警功能。

缺省情况下，未使能ARP报文限速丢弃告警功能。

步骤6 （可选）执行命令**arp anti-attack rate-limit alarm threshold threshold**，配置ARP报文限速丢弃告警阈值。

缺省情况下，ARP报文限速丢弃告警阈值为100。

----结束

11.6.1.4 配置 ARP 报文限速（针对 Super VLAN 的 VLANIF 接口）

背景信息

以下两种情况会触发Super VLAN的VLANIF接口进行ARP学习：

- VLANIF接口接收到触发ARP Miss消息的IP报文
- VLANIF接口上启用ARP代理功能之后，设备接收到目的IP符合代理条件且该IP对应的ARP条目不存在的ARP请求报文

Super VLAN的VLANIF接口进行ARP学习时会将ARP请求报文在每个Sub VLAN下复制，如果该Super VLAN下配置了大量Sub VLAN，那么设备将产生大量的ARP请求报文。为了避免CPU因复制、发送大量ARP请求报文而负担过重，设备支持Super VLAN的VLANIF接口下的ARP报文限速功能，以对该场景下设备发送的ARP请求报文进行流量控制。

当设备CPU较为繁忙时，可适当调小ARP请求报文的广播发送限制速率；当设备CPU较为空闲时，且希望能够快速广播ARP请求报文，则可以适当调大该速率。请根据设备实际状况和实际网络环境进行调整。

建议在网关设备上进行如下配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp speed-limit flood-rate rate**，配置所有Super VLAN的VLANIF接口下ARP请求报文的广播发送限制速率。

缺省情况下，所有Super VLAN的VLANIF接口下ARP请求报文的广播发送限制速率为1000pps。

----结束

11.6.1.5 配置 ARP Miss 消息限速（根据源 IP 地址）

背景信息

如果网络中有用户向设备发送大量目标IP地址不能解析的IP报文（即路由表中存在该IP报文的目的IP对应的路由表项，但设备上没有该路由表项中下一跳对应的ARP表项），将导致设备触发大量的ARP Miss消息。这种触发ARP Miss消息的IP报文会被上送到设备进行处理，设备会根据ARP Miss消息生成和下发大量临时ARP表项并向目的网络发

送大量ARP请求报文，这样就增加了设备CPU的负担，同时严重消耗目的网络的带宽资源。

当设备检测到某一源IP地址的IP报文在1秒内触发的ARP Miss消息数量超过了限速值，就认为此源IP地址存在攻击。

管理员可以根据实际网络环境，对ARP Miss消息的限速值进行调整，限制设备在一定时间内只处理指定数目的ARP Miss消息，避免设备的资源浪费在处理ARP Miss消息上，保证用户的其他业务能够正常运行。

建议在网关设备上进行如下配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置根据源IP地址进行ARP Miss消息限速

- 执行命令**arp-miss speed-limit source-ip maximum maximum**，配置根据源IP地址进行ARP Miss消息限速的限速值。
- 执行命令**arp-miss speed-limit source-ip ip-address maximum maximum**，配置对指定IP地址用户的ARP Miss消息进行限速的限速值。

两种配置同时存在的条件下，当触发ARP Miss消息的IP报文的源IP地址匹配限速指定的IP地址时，对该源IP地址的IP报文触发的ARP Miss消息限速值为后一步骤中配置的**maximum**值；否则为前一步骤中配置的**maximum**值。

如果将限速值配置为0，则表示不根据源IP地址进行ARP Miss消息限速。缺省情况下，设备允许每秒最多处理同一个源IP地址触发的5个ARP Miss消息。

----结束

11.6.1.6 配置 ARP Miss 消息限速（针对全局）

背景信息

如果网络中有用户向设备发送大量目标IP地址不能解析的IP报文（即路由表中存在该IP报文的的目的IP对应的路由表项，但设备上没有该路由表项中下一跳对应的ARP表项），将导致设备触发大量的ARP Miss消息。这种触发ARP Miss消息的IP报文会被上送到设备进行处理，设备会根据ARP Miss消息生成和下发大量临时ARP表项并向目的网络发送大量ARP请求报文，这样就增加了设备CPU的负担，同时严重消耗目的网络的带宽资源。

为了避免这种IP报文攻击所带来的危害，建议在网关设备上配置ARP Miss消息限速功能。

当设备忽略的ARP Miss消息数量较多时，如果希望设备能够以告警的方式提醒网络管理员，则可以配置ARP Miss消息限速丢弃告警功能。当设备忽略处理的ARP Miss消息个数超过告警阈值时，设备将产生告警。

说明

如果配置了ARP Miss消息限速丢弃告警功能，则需使用命令**arp anti-attack log-trap-timer time**调整设备发送告警的时间间隔。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp-miss anti-attack rate-limit enable**，使能ARP Miss消息限速功能。

缺省情况下，未使能ARP Miss消息限速功能。

步骤3 执行命令**arp-miss anti-attack rate-limit packet-number [interval-value]**，配置ARP Miss消息的限速值和限速时间。

缺省情况下，在1秒内设备最多允许处理100个ARP Miss消息。

步骤4 （可选）执行命令**arp-miss anti-attack rate-limit alarm enable**，使能ARP Miss消息限速丢弃告警功能。

缺省情况下，未使能ARP Miss消息限速丢弃告警功能。

步骤5 （可选）执行命令**arp-miss anti-attack rate-limit alarm threshold threshold**，配置ARP Miss消息限速丢弃告警阈值。

缺省情况下，ARP Miss消息限速丢弃告警阈值为100。

----结束

11.6.1.7 配置临时 ARP 表项的老化时间

背景信息

当IP报文触发ARP Miss消息时，设备会根据ARP Miss消息生成临时ARP表项，并且向目的网段发送ARP请求报文。

- 在临时ARP表项老化时间范围内：
 - 设备收到ARP应答报文前，匹配临时ARP表项的IP报文将被丢弃并且不会触发ARP Miss消息。
 - 设备收到ARP应答报文后，则生成正确的ARP表项来替换临时ARP表项。
- 当老化时间超时后，设备会清除临时ARP表项。此时如果设备转发IP报文匹配不到对应的ARP表项，则会重新触发ARP Miss消息并生成临时ARP表项，如此循环重复。

故可以通过配置临时ARP表项的老化时间来控制ARP Miss消息的触发频率。当判断设备受到攻击时，可以调大该时间，减小设备ARP Miss消息的触发频率，从而减小攻击对设备的影响。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface interface-type interface-number**，进入接口视图。

接口类型包括Ethernet、GE、Eth-Trunk和VLANIF。

步骤3 执行命令**arp-fake expire-time expire-time**，配置临时ARP表项的老化时间。

缺省情况下，临时ARP表项的老化时间是1秒。

----结束

11.6.1.8 配置 ARP 表项严格学习

背景信息

如果大量用户在同一时间段内向设备发送大量ARP报文，或者攻击者伪造正常用户的ARP报文发送给设备，则会造成如下危害：

- 设备因处理大量ARP报文而导致CPU负荷过重，同时设备学习大量的ARP报文可能导致设备ARP表项资源被无效的ARP条目耗尽，造成合法用户的ARP报文不能继续生成ARP条目，导致用户无法正常通信。
- 伪造的ARP报文将错误地更新设备ARP表项，导致合法用户无法正常通信。

为避免上述危害，可以在网关设备上配置ARP表项严格学习功能。配置该功能后，只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP，这样，可以拒绝大部分的ARP报文攻击。

ARP表项严格学习功能可在全局和接口视图下进行配置。

- 全局使能该功能，则设备的所有接口均进行ARP表项严格学习。
- 接口视图下使能该功能，则只有该接口进行ARP表项严格学习。

当同时在全局和接口视图下进行配置时，接口下配置的优先级高于全局配置的优先级。

说明

在全局使能ARP表项严格学习功能的前提下：

- 如果在指定接口下执行命令**arp learning strict force-disable**，则该接口将会被强制执行去使能ARP表项严格学习的功能。
- 如果在指定接口下执行命令**arp learning strict trust**时，则该接口的ARP表项严格学习功能和全局的配置保持一致。

操作步骤

- 配置全局ARP表项严格学习功能
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**arp learning strict**，配置全局ARP表项严格学习功能。

缺省情况下，未使能ARP表项严格学习功能。
- 配置接口的ARP表项严格学习功能
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**interface interface-type interface-number**，进入接口视图。
 - c. 执行命令**arp learning strict { force-enable | force-disable | trust }**，配置接口的ARP表项严格学习功能。

缺省情况下，未使能ARP表项严格学习功能。

----结束

11.6.1.9 配置基于接口的 ARP 表项限制

背景信息

为了防止当一个接口所接入的某一用户主机发起ARP攻击时导致整个设备的ARP表资源都被耗尽，可以在指定接口下配置接口能够学习到的最大动态ARP表项数目。当指定接口下的动态ARP表项达到允许学习的最大数目后，将不允许新增动态ARP表项。

建议在网关设备上进行如下配置。

操作步骤

- 配置以太网接口的ARP表项限制
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**interface interface-type interface-number**，进入接口视图。
 - c. 执行命令**arp-limit vlan vlan-id1 [to vlan-id2] maximum maximum**，配置基于以太网接口的ARP表项限制。

缺省情况下，设备接口能学到的最大动态ARP表项数目是该接口下能配置的最大值。

接口类型包括Ethernet、GE、VE和Eth-Trunk。这些接口既可以是三层接口也可以是二层接口。作为三层接口时，不能配置vlan-id。作为二层接口时，必须配置vlan-id。
- 配置VLANIF接口的ARP表项限制
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**interface vlanif interface-number**，进入VLANIF接口视图。
 - c. 执行命令**arp-limit maximum maximum**，配置基于VLANIF接口的ARP表项限制。

缺省情况下，设备接口能学到的最大动态ARP表项数目是该接口下能配置的最大值。
- 配置以太网子接口的ARP表项限制
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**interface interface-type interface-number [.subnumber]**，进入子接口视图。
 - c. 执行命令**arp-limit vlan vlan-id1 [to vlan-id2] maximum maximum**，配置基于物理子接口的ARP表项限制。

缺省情况下，设备接口能学到的最大动态ARP表项数目是该接口下能配置的最大值。

接口类型包括Ethernet、GE、VE和Eth-Trunk。这些接口既可以是三层接口也可以是二层接口。作为三层接口时，不能配置vlan-id。作为二层接口时，必须配置vlan-id。

----结束

11.6.1.10 检查防 ARP 泛洪攻击配置结果

操作步骤

- 使用命令**display arp anti-attack configuration { arp-rate-limit | arpmis-rate-limit | arp-speed-limit | arpmis-speed-limit | entry-check | gateway-duplicate | packet-check | all }**，查看ARP防攻击配置。
- 使用命令**display arp-limit [interface interface-type interface-number] [vlan vlan-id]**，查看接口可以学习到的动态ARP表项数目的最大值。
- 使用命令**display arp learning strict**，查看全局和所有接口上的ARP表项严格学习情况。

----结束

11.6.2 配置防 ARP 欺骗攻击

通过配置防ARP欺骗攻击功能，可以防止伪造的ARP报文恶意修改设备或网络内其他用户主机的ARP表项，造成网络中的报文转发异常。

前置任务

在配置防ARP欺骗攻击之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。

配置流程

在配置防ARP欺骗攻击任务中，各配置步骤均是并列关系，无严格配置顺序，用户根据需要选择配置即可。

11.6.2.1 配置 ARP 表项固化

背景信息

为了防止ARP地址欺骗攻击，可以在网关设备上配置ARP表项固化功能。三种ARP表项固化模式适用于不同的应用场景，且是互斥关系。

- **fixed-mac**方式：设备收到的ARP报文中的MAC地址与ARP表中对应条目的MAC地址不匹配，则直接丢弃该ARP报文；如果匹配，但是收到报文的接口或VLAN信息与ARP表中对应条目不匹配，则可以更新对应ARP条目中的接口和VLAN信息。此方式适用于用户MAC地址固定，但用户接入位置频繁变动的场景。当用户从不同接口接入设备时，设备上该用户对应的ARP表项中的接口信息可以及时更新。
- **fixed-all**方式：只有当ARP报文对应的MAC地址、接口、VLAN信息和ARP表项中的信息完全匹配时，设备才可以更新ARP表项的其他内容。此方式适用于用户MAC地址固定，并且用户接入位置相对固定的场景。
- **send-ack**方式：设备收到一个涉及MAC地址、VLAN、接口修改的ARP报文时，不会立即更新ARP表项，而是先向待更新的ARP表项现有MAC地址对应的用户发送一个单播的ARP请求报文进行确认，根据确认结果再决定是否更新ARP表项中的MAC地址、VLAN和接口信息。此方式适用于用户的MAC地址和接入位置均频繁变动的场景。

可在全局下配置ARP表项固化功能。全局配置该功能后，默认设备上所有接口的ARP表项固化功能均已使能。

操作步骤

- 全局使能ARP表项固化功能
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**arp anti-attack entry-check { fixed-mac | fixed-all | send-ack } enable**，配置ARP表项固化功能。

缺省情况下，未配置ARP表项固化功能。

----结束

11.6.2.2 配置动态 ARP 检测

背景信息

为了防御中间人攻击，避免合法用户的数据被中间人窃取，可以在接入设备上使能动态ARP检测DAI功能。设备会将ARP报文对应的源IP、源MAC、接口、VLAN信息和绑定表中的信息进行比较，如果信息匹配，说明发送该ARP报文的用户是合法用户，允许此用户的ARP报文通过，否则就认为是攻击，丢弃该ARP报文。

可在接口视图或VLAN视图下使能动态ARP检测功能。在接口视图下使能时，则对该接口收到的所有ARP报文进行绑定表匹配检查；在VLAN视图下使能时，则对加入该VLAN的接口收到的属于该VLAN的ARP报文进行绑定表匹配检查。

当设备丢弃的不匹配绑定表的ARP报文数量较多时，如果希望设备能够以告警的方式提醒网络管理员，则可以使能动态ARP检测丢弃报文告警功能。当丢弃的ARP报文数超过告警阈值时，设备将产生告警。

说明

当网关设备上部署了DHCP触发ARP学习功能时，则可以在网关设备上部署本功能。

本功能仅适用于DHCP Snooping场景。设备使能DHCP Snooping功能后，当DHCP用户上线时，设备会自动生成DHCP Snooping绑定表；对于静态配置IP地址的用户，设备不会生成DHCP Snooping绑定表，所以需要手动添加静态绑定表。DHCP Snooping的配置，请参见[13 DHCP Snooping配置](#)。静态绑定表的配置，请参见[14.6.1 配置基于静态绑定表的IPSG](#)。

在设备上配置动态ARP检测功能时，还需同时配置端口隔离和ARP代理功能，否则动态ARP检测功能无法生效。端口隔离的配置，请参见《AR300, AR700 配置指南-接口管理》中的“配置端口隔离”。ARP代理的配置，请参见《AR300, AR700 配置指南-IP业务》中的“配置Proxy ARP”。

操作步骤

- 步骤1** 执行命令**system-view**，进入系统视图。
- 步骤2** 执行命令**interface interface-type interface-number**，进入接口视图；或者执行命令**vlan vlan-id**，进入VLAN视图。
- 步骤3** 执行命令**arp anti-attack check user-bind enable**，使能动态ARP检测功能（即对ARP报文进行绑定表匹配检查功能）。

缺省情况下，未使能动态ARP检测功能。
- 步骤4** （可选）接口视图下执行命令**arp anti-attack check user-bind check-item { ip-address | mac-address | vlan }**，或者VLAN视图下执行命令**arp anti-attack check user-bind check-item { ip-address | mac-address | interface }**，配置对ARP报文进行绑定表匹配检查的检查项。

缺省情况下，对ARP报文的IP地址、MAC地址、VLAN和接口信息都进行检查。

如果希望仅匹配绑定表某一项或某两项内容的特殊ARP报文也能够通过，则可以配置对ARP报文进行绑定表匹配检查时只检查某一项或某两项内容。

说明

指定ARP报文绑定表匹配检查项对配置了静态绑定表的用户不起作用，即设备仍然按照静态绑定表的内容对ARP报文进行绑定表匹配检查。

步骤5 （可选）接口视图下执行命令**arp anti-attack check user-bind alarm enable**，使能动态ARP检测丢弃报文告警功能。

缺省情况下，未使能动态ARP检测丢弃报文告警功能。

须知

由于动态ARP检测丢弃报文告警功能针对的是接口下DAI功能丢弃的ARP报文数告警统计，因此建议不要同时在VLAN视图下配置命令**arp anti-attack check user-bind enable**以及在加入该VLAN的接口视图下配置命令**arp anti-attack check user-bind alarm enable**，避免VLAN下的DAI功能可能造成实际丢包数目和接口DAI告警统计值之间的偏差。

由于设备缺省的发送ARP告警的时间间隔为0（即不发送ARP告警信息），因此使能动态ARP检测丢弃报文告警功能后，必须使用命令**arp anti-attack log-trap-timer time**调大设备发送告警的时间间隔，设备才会发送ARP告警。

步骤6 （可选）接口视图下执行命令**arp anti-attack check user-bind alarm threshold threshold**，配置动态ARP检测丢弃报文告警阈值。

缺省情况下，动态ARP检测丢弃报文告警阈值为系统视图下**arp anti-attack check user-bind alarm threshold threshold**命令配置的值。如果系统视图下没有配置该值，则接口下缺省的告警阈值为100。

----结束

11.6.2.3 配置 ARP 防网关冲突

背景信息

如果有攻击者仿冒网关，在局域网内部发送源IP地址是网关IP地址的ARP报文，会导致局域网内其他用户主机的ARP表记录错误的网关地址映射关系。这样其他用户主机就会把发往网关的流量均发送给了攻击者，攻击者可轻易侦听到他们发送的数据内容，并且最终会造成这些用户主机无法访问网络。

为了防范攻击者仿冒网关，当用户主机直接接入网关时，可以在网关设备上使能ARP防网关冲突攻击功能。当设备收到的ARP报文存在下列情况之一：

- ARP报文的源IP地址与报文入接口对应的VLANIF接口的IP地址相同
- ARP报文的源IP地址是入接口的虚拟IP地址，但ARP报文源MAC地址不是VRRP虚MAC

设备就认为该ARP报文是与网关地址冲突的ARP报文，设备将生成ARP防攻击表项，并在后续一段时间内丢弃该接口收到的同VLAN以及同源MAC地址的ARP报文，这样就可以防止与网关地址冲突的ARP报文在VLAN内广播。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp anti-attack gateway-duplicate enable**，使能ARP防网关冲突攻击功能。

缺省情况下，未使能ARP防网关冲突攻击功能。

----结束

11.6.2.4 配置发送 ARP 免费报文

背景信息

如果有攻击者向其他用户发送仿冒网关的ARP报文，会导致其他用户的ARP表中记录错误的网关地址映射关系，造成其他用户的正常数据不能被网关接收。此时可以在网关设备上配置发送免费ARP报文的功能，用来定期更新合法用户的ARP表项，使得合法用户ARP表项中记录的是正确的网关地址映射关系。

可在全局或VLANIF接口下配置发送免费ARP报文功能。

- 全局配置该功能后，则默认设备上所有接口的发送ARP免费报文功能均已使能。
- 当全局和VLANIF接口下同时配置了该功能时，VLANIF接口下的配置优先生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 （可选）执行命令**interface vlanif interface-number**，进入VLANIF接口视图。

📖 说明

在系统视图下配置发送ARP免费报文功能无需执行此步骤。

步骤3 执行命令**arp gratuitous-arp send enable**，使能发送免费ARP报文的功能。

缺省情况下，未使能发送免费ARP报文的功能。

步骤4 （可选）执行命令**arp gratuitous-arp send interval interval-time**，配置发送免费ARP报文的时间间隔。

缺省情况下，发送免费ARP报文的时间间隔为90秒。

----结束

11.6.2.5 配置 ARP 报文内 MAC 地址一致性检查

背景信息

ARP报文内MAC地址一致性检查功能主要应用于网关设备上，可以防御以太网数据帧首部中的源/目的MAC地址和ARP报文数据区中的源/目的MAC地址不同的ARP攻击。

配置ARP报文内MAC地址一致性检查后，网关设备在进行ARP学习前将对ARP报文进行检查。如果以太网数据帧首部中的源/目的MAC地址和ARP报文数据区中的源/目的MAC地址不同，则认为是攻击报文，将其丢弃；否则，继续进行ARP学习。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface interface-type interface-number**，进入接口视图。

步骤3 执行命令**arp validate { source-mac | destination-mac } ***，使能ARP报文内MAC地址一致性检查功能，即设备对以太网数据帧首部中的源/目的MAC地址和ARP报文数据区中的源/目的MAC地址进行一致性检查的功能。

缺省情况下，设备不对以太网数据帧首部中的源/目的MAC地址和ARP报文数据区中的源/目的MAC地址进行一致性检查。

说明

本命令不支持在子接口上配置。当子接口收到ARP报文时，ARP报文内MAC地址一致性检查遵循主接口下的检查规则。

本命令不支持在VLANIF接口上配置。当VLANIF接口收到ARP报文时，ARP报文内MAC地址一致性检查遵循成员口下的检查规则。

----结束

11.6.2.6 配置 ARP 报文合法性检查

背景信息

设备在收到ARP报文时，会对ARP报文的有效性进行检查，检查的项目包含但不限于：

- 检查报文的长度
- 以太网数据帧首部中的源MAC、目的MAC合法性检查
- ARP请求、回应类型检查
- MAC地址长度检查
- IP地址长度检查
- ARP帧格式是否为以太网帧类型检查

这些检查是用来判断ARP报文的格式跟ARP协议的规定是否一致。其中以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址不一致的ARP报文是协议允许的报文，但是在实际的应用中，该类报文很可能是攻击报文。

使能ARP报文合法性检查功能后，设备会对收到的ARP报文进行以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址的一致性检查，如果两者不一致，则直接丢弃该ARP报文，否则允许该ARP报文通过。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp anti-attack packet-check sender-mac**，使能ARP报文合法性检查功能，即对ARP报文中的源MAC地址和以太网数据帧首部中的源MAC地址进行一致性检查的功能。

缺省情况下，未使能ARP报文合法性检查功能。

----结束

11.6.2.7 配置 ARP 表项严格学习

背景信息

如果大量用户在同一时间段内向设备发送大量ARP报文，或者攻击者伪造正常用户的ARP报文发送给设备，则会造成如下危害：

- 设备因处理大量ARP报文而导致CPU负荷过重，同时设备学习大量的ARP报文可能导致设备ARP表项资源被无效的ARP条目耗尽，造成合法用户的ARP报文不能继续生成ARP条目，导致用户无法正常通信。
- 伪造的ARP报文将错误地更新设备ARP表项，导致合法用户无法正常通信。

为避免上述危害，可以在网关设备上配置ARP表项严格学习功能。配置该功能后，只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP，这样，可以拒绝大部分的ARP报文攻击。

ARP表项严格学习功能可在全局和接口视图下进行配置。

- 全局使能该功能，则设备的所有接口均进行ARP表项严格学习。
- 接口视图下使能该功能，则只有该接口进行ARP表项严格学习。

当同时在全局和接口视图下进行配置时，接口下配置的优先级高于全局配置的优先级。

说明

在全局使能ARP表项严格学习功能的前提下：

- 如果在指定接口下执行命令**arp learning strict force-disable**，则该接口将会被强制执行去使能ARP表项严格学习的功能。
- 如果在指定接口下执行命令**arp learning strict trust**时，则该接口的ARP表项严格学习功能和全局的配置保持一致。

操作步骤

- 配置全局ARP表项严格学习功能
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**arp learning strict**，配置全局ARP表项严格学习功能。

缺省情况下，未使能ARP表项严格学习功能。
- 配置接口的ARP表项严格学习功能
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**interface interface-type interface-number**，进入接口视图。
 - c. 执行命令**arp learning strict { force-enable | force-disable | trust }**，配置接口的ARP表项严格学习功能。

缺省情况下，未使能ARP表项严格学习功能。

----结束

11.6.2.8 配置 DHCP 触发 ARP 学习

背景信息

在DHCP用户场景下，当DHCP用户数目很多时，设备进行大规模ARP表项的学习和老化会对设备性能和网络环境形成冲击。

为了避免此问题，可以在网关设备上使能DHCP触发ARP学习功能。当DHCP服务器给用户分配了IP地址，网关设备会根据VLANIF接口上收到的DHCP ACK报文直接生成该用户的ARP表项。

说明

DHCP触发ARP学习功能生效的前提是通过命令**dhcp snooping enable**使能DHCP Snooping功能。

在VRRP和DHCP Relay组合场景下，VRRP主备设备上都不能再配置命令**dhcp snooping enable**和**arp learning dhcp-trigger**。

网关设备上还可同时部署**动态ARP检测功能**，防止DHCP用户的ARP表项被伪造的ARP报文恶意修改。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface vlanif *vlan-id***，进入VLANIF接口视图。

步骤3 执行命令**arp learning dhcp-trigger**，使能DHCP触发ARP学习功能。

缺省情况下，未使能DHCP触发ARP学习功能。

----结束

11.6.2.9 检查防 ARP 欺骗攻击配置结果

操作步骤

- 使用命令**display arp anti-attack configuration { arp-rate-limit | arpmis-rate-limit | arp-speed-limit | arpmis-speed-limit | entry-check | gateway-duplicate | packet-check | all }**，查看ARP防攻击配置。
- 使用命令**display arp anti-attack check user-bind interface *interface-type interface-number***，查看接口下ARP报文检查相关的配置。
- 使用命令**display arp learning strict**，查看全局和所有接口上的ARP表项严格学习情况。
- 使用命令**display arp anti-attack gateway-duplicate item**，查看ARP防网关冲突攻击表项。

----结束

11.7 维护 ARP 安全

维护ARP安全包括监控ARP运行情况、清除ARP报文统计信息、清除ARP报文丢弃计数以及配置对潜在的ARP攻击行为发送日志和告警。

11.7.1 监控 ARP 安全运行情况

操作步骤

- 执行命令**display arp packet statistics**，查看ARP处理的报文统计数据。
- 执行命令**display arp flood statistics**，查看所有Super VLAN的VLANIF接口下ARP请求报文的发送统计信息。

----结束

11.7.2 清除 ARP 安全统计信息

背景信息

须知

清除统计信息后，以前的统计信息将无法恢复，务必仔细确认。

在确认需要清除运行信息后，请在用户视图下执行下列命令。

操作步骤

- 执行命令**reset arp packet statistics**，清除ARP报文的统计信息。
- 执行命令**reset arp flood statistics**，清除所有Super VLAN的VLANIF接口下ARP请求报文的发送统计信息。
- 执行命令**reset arp anti-attack statistics check user-bind interface *interface-type interface-number***，清除由于不匹配绑定表而丢弃的ARP报文计数。
- 执行命令**reset arp anti-attack statistics rate-limit { **global** | **interface** *interface-type interface-number* }**，清除由于ARP报文超过速率限制阈值而被丢弃的计数。

----结束

11.7.3 配置对潜在的 ARP 攻击行为发送告警

背景信息

为了使管理员能够实时的了解设备上ARP运行情况，对潜在的攻击行为作出判断和应对措施，设备支持对潜在的攻击行为发送告警，实时记录ARP运行的异常情况。通过配置发送告警的时间间隔，可以减少告警发送的数量，以避免ARP攻击时造成海量告警信息。

说明

该配置只能对以下告警生效：

- SECE_1.3.6.1.4.1.2011.5.25.165.2.2.2.4 hwARPSDaiDropALarm
- SECE_1.3.6.1.4.1.2011.5.25.165.2.2.2.5 hwARPGlobleSpeedLimitALarm
- SECE_1.3.6.1.4.1.2011.5.25.165.2.2.2.8 hwARPMissGlobeSpeedLimitALarm
- SECE_1.3.6.1.4.1.2011.5.25.165.2.2.2.3 hwARPSPacketCheck
- SECE_1.3.6.1.4.1.2011.5.25.165.2.2.2.1 hwARPSGatewayConflict
- SECE_1.3.6.1.4.1.2011.5.25.165.2.2.2.2 hwARPSEntryCheck

操作步骤

步骤1 执行命令`system-view`，进入系统视图。

步骤2 执行命令`arp anti-attack log-trap-timer time`，配置对潜在的ARP攻击行为发送告警的时间间隔。

缺省情况下，发送ARP告警时间间隔为0，即设备不发送ARP告警信息。

----结束

11.8 ARP 安全配置举例

介绍ARP安全配置举例。配置示例中包括组网需求、配置思路、配置过程等。

11.8.1 配置 ARP 安全综合功能示例

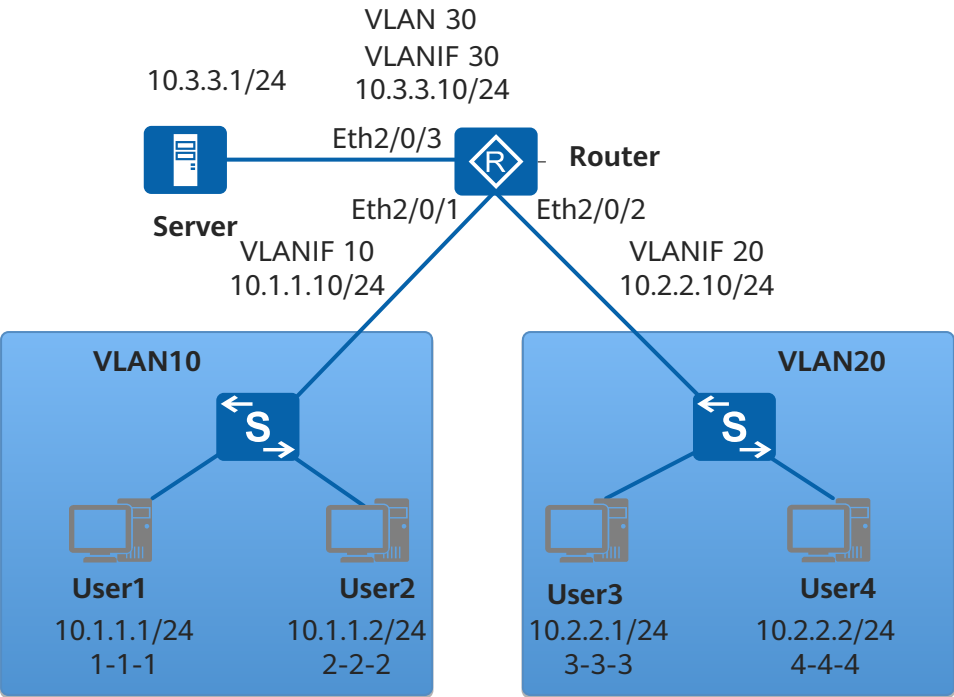
组网需求

如图11-9所示，Router通过接口Eth2/0/3连接一台服务器，通过接口Eth2/0/1、Eth2/0/2连接VLAN10和VLAN20下的四个用户。网络中存在以下ARP威胁：

- 攻击者向Router发送伪造的ARP报文、伪造的免费ARP报文进行ARP欺骗攻击，恶意修改Router的ARP表项，造成其他用户无法正常接收数据报文。
- 攻击者发出大量目的IP地址不可达的IP报文进行ARP泛洪攻击，造成Router的CPU负荷过重。
- 用户User1构造大量源IP地址变化MAC地址固定的ARP报文进行ARP泛洪攻击，造成Router的ARP表资源被耗尽以及CPU进程繁忙，影响到正常业务的处理。
- 用户User3构造大量源IP地址固定的ARP报文进行ARP泛洪攻击，造成Router的CPU进程繁忙，影响到正常业务的处理。

管理员希望能够防止上述ARP攻击行为，为用户提供更安全的网络环境和更稳定的网络服务。

图 11-9 配置 ARP 安全功能组网图



配置思路

采用如下思路在Router上进行配置：

- 1. 配置ARP表项严格学习功能以及ARP表项固化功能，实现防止伪造的ARP报文错误地更新Router的ARP表项。
- 2. 配置根据源IP地址进行ARP Miss消息限速，实现防止用户侧存在攻击者发出大量目的IP地址不可达的IP报文触发大量ARP Miss消息，形成ARP泛洪攻击。同时需要保证Router可以正常处理服务器发出的大量此类报文，避免因丢弃服务器发出的大量此类报文而造成网络无法正常通信。
- 3. 配置基于接口的ARP表项限制以及根据源MAC地址进行ARP限速，实现防止User1发送的大量源IP地址变化MAC地址固定的ARP报文形成的ARP泛洪攻击，避免Router的ARP表资源被耗尽，并避免CPU进程繁忙。
- 4. 配置根据源IP地址进行ARP限速，实现防止User3发送的大量源IP地址固定的ARP报文形成的ARP泛洪攻击，避免Router的CPU进程繁忙。

操作步骤

步骤1 创建VLAN，将接口加入到VLAN中，并配置VLANIF接口。

创建VLAN 10、VLAN 20和VLAN 30，并将接口Eth2/0/1加入VLAN 10中，接口Eth2/0/2加入VLAN 20中，接口Eth2/0/3加入VLAN 30中。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10 20 30
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type trunk
[Router-Ethernet2/0/1] port trunk allow-pass vlan 10
```

```
[Router-Ethernet2/0/1] quit
[Router] interface ethernet 2/0/2
[Router-Ethernet2/0/2] port link-type trunk
[Router-Ethernet2/0/2] port trunk allow-pass vlan 20
[Router-Ethernet2/0/2] quit
[Router] interface ethernet 2/0/3
[Router-Ethernet2/0/3] port link-type trunk
[Router-Ethernet2/0/3] port trunk allow-pass vlan 30
[Router-Ethernet2/0/3] quit
```

创建接口VLANIF 10、VLANIF 20、VLANIF 30，配置各VLANIF接口的IP地址。

```
[Router] interface vlanif 10
[Router-Vlanif10] ip address 10.1.1.10 24
[Router-Vlanif10] quit
[Router] interface vlanif 20
[Router-Vlanif20] ip address 10.2.2.10 24
[Router-Vlanif20] quit
[Router] interface vlanif 30
[Router-Vlanif30] ip address 10.3.3.10 24
[Router-Vlanif30] quit
```

步骤2 配置ARP表项严格学习功能。

```
[Router] arp learning strict
```

步骤3 配置ARP表项固化功能。

配置ARP表项固化模式为fixed-mac方式。

```
[Router] arp anti-attack entry-check fixed-mac enable
```

步骤4 配置根据源IP地址进行ARP Miss消息限速。

配置对Server（IP地址为10.3.3.1）的ARP Miss消息进行限速，允许Router每秒最多处理该IP地址触发的40个ARP Miss消息；对于其他用户，允许Router每秒最多处理同一个源IP地址触发的20个ARP Miss消息。

```
[Router] arp-miss speed-limit source-ip maximum 20
[Router] arp-miss speed-limit source-ip 10.3.3.1 maximum 40
```

步骤5 配置基于接口的ARP表项限制。

配置接口Eth2/0/1最多可以学习到20个动态ARP表项。

```
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] arp-limit vlan 10 maximum 20
[Router-Ethernet2/0/1] quit
```

步骤6 配置根据源MAC地址进行ARP限速。

配置对用户User1（MAC地址为00e0-fc01-0101）进行ARP报文限速，每秒最多只允许10个该MAC地址的ARP报文通过。

```
[Router] arp speed-limit source-mac 00e0-fc01-0101 maximum 10
```

步骤7 配置根据源IP地址进行ARP限速。

配置对用户User3（IP地址为10.2.2.1）进行ARP报文限速，每秒最多只允许10个该IP地址的ARP报文通过。

```
[Router] arp speed-limit source-ip 10.2.2.1 maximum 10
```

步骤8 验证配置结果。

执行命令**display arp learning strict**，可以看到全局已经配置ARP表项严格学习功能。

```
[Router] display arp learning strict
The global configuration:arp learning strict
Interface                LearningStrictState
-----
Total:0
Force-enable:0
Force-disable:0
```

执行命令**display arp-limit**，查看接口可以学习到的动态ARP表项数目的最大值。

```
[Router] display arp-limit interface ethernet 2/0/1
Interface          LimitNum  VlanID  LearnedNum(Mainboard)
-----
Ethernet2/0/1      20       10      0
Total:1
```

执行命令**display arp anti-attack configuration all**，查看当前ARP防攻击配置情况。

```
[Router] display arp anti-attack configuration all

ARP anti-attack packet-check function: disable

ARP anti-attack entry-check mode: fixed-mac

ARP gateway-duplicate anti-attack function: disabled

ARP rate-limit configuration:
-----
Global configuration:
Interface configuration:
-----

ARP miss rate-limit configuration:
-----
Global configuration:
-----

ARP speed-limit for source-MAC configuration:
MAC-address      suppress-rate(pps)(rate=0 means function disabled)
-----
00e0-fc01-0101   10
Others           0
-----
1 specified MAC addresses are configured, spec is 256 items.

ARP speed-limit for source-IP configuration:
IP-address       suppress-rate(pps)(rate=0 means function disabled)
-----
10.2.2.1        10
Others          5
-----
1 specified IP addresses are configured, spec is 256 items.

ARP miss speed-limit for source-IP configuration:
IP-address       suppress-rate(pps)(rate=0 means function disabled)
-----
10.3.3.1        40
Others          20
-----
1 specified IP addresses are configured, spec is 256 items.
```

执行命令**display arp packet statistics**，查看ARP处理的报文统计数据。

```
[Router] display arp packet statistics
ARP Pkt Received: sum 8678904
ARP Learnt Count: sum 37
ARP Pkt Discard For Limit: sum 146
```

```
ARP Pkt Discard For SpeedLimit: sum 40529
ARP Pkt Discard For Proxy Suppress: sum 0
ARP Pkt Discard For Other: sum 8367601
```

由显示信息可知，Router上产生了ARP报文丢弃计数，表明ARP安全功能已经生效。

----结束

配置文件

Router的配置文件

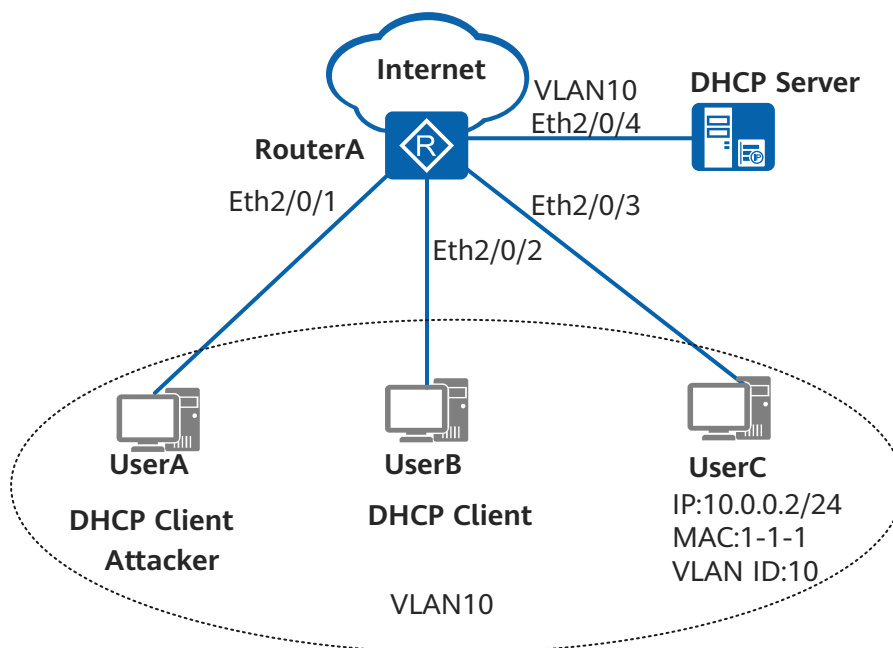
```
#
sysname Router
#
vlan batch 10 20 30
#
arp-miss speed-limit source-ip maximum 20
#
arp learning strict
#
arp-miss speed-limit source-ip 10.3.3.1 maximum 40
arp speed-limit source-ip 10.2.2.1 maximum 10
arp speed-limit source-mac 00e0-fc01-0101 maximum 10
arp anti-attack entry-check fixed-mac enable
#
interface Vlanif10
ip address 10.1.1.10 255.255.255.0
#
interface Vlanif20
ip address 10.2.2.10 255.255.255.0
#
interface Vlanif30
ip address 10.3.3.10 255.255.255.0
#
interface Ethernet2/0/1
port link-type trunk
port trunk allow-pass vlan 10
arp-limit vlan 10 maximum 20
#
interface Ethernet2/0/2
port link-type trunk
port trunk allow-pass vlan 20
#
interface Ethernet2/0/3
port link-type trunk
port trunk allow-pass vlan 30
#
return
```

11.8.2 配置防止 ARP 中间人攻击示例

组网需求

如图11-10所示，企业某部门用户通过RouterA接入Internet。RouterA下挂的用户，有些采用DHCP方式获取IP地址，有些采用静态配置的IP地址，且所有用户和DHCP Server均位于同一VLAN。如果存在攻击者发起ARP中间人攻击，会造成合法用户的数据的泄漏，因此管理员希望RouterA能够防止ARP中间人攻击，同时希望能够了解RouterA受到ARP中间人攻击的频率和范围。

图 11-10 配置防止 ARP 中间人攻击组网图



配置思路

采用如下思路在RouterA上进行配置：

1. 配置DHCP Snooping功能，以便生成动态用户的地址和端口的绑定关系表，并为静态用户配置静态绑定表，用于后续的ARP报文合法性检查。
2. 使能动态ARP检测功能，使RouterA对收到的ARP报文对应的源IP、源MAC、VLAN和接口信息进行绑定表匹配检查，过滤非法ARP报文，从而防止ARP中间人攻击。
3. 使能动态ARP检测丢弃报文告警功能，使RouterA对丢弃的不匹配绑定表的ARP报文数量进行统计，并在丢弃数量超过告警阈值时能以告警的方式提醒管理员。管理员根据告警信息以及报文丢弃计数可以了解RouterA受到ARP中间人攻击的频率和范围。

操作步骤

步骤1 创建VLAN，将接口加入到VLAN中

创建VLAN 10，并将接口Eth2/0/1、Eth2/0/2、Eth2/0/3、Eth2/0/4加入VLAN 10中。

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] vlan batch 10
[RouterA] interface ethernet 2/0/1
[RouterA-Ethernet2/0/1] port link-type access
[RouterA-Ethernet2/0/1] port default vlan 10
[RouterA-Ethernet2/0/1] quit
[RouterA] interface ethernet 2/0/2
[RouterA-Ethernet2/0/2] port link-type access
[RouterA-Ethernet2/0/2] port default vlan 10
[RouterA-Ethernet2/0/2] quit
```



```
[RouterA] interface ethernet 2/0/3
[RouterA-Ethernet2/0/3] port link-type access
[RouterA-Ethernet2/0/3] port default vlan 10
[RouterA-Ethernet2/0/3] quit
[RouterA] interface ethernet 2/0/4
[RouterA-Ethernet2/0/4] port link-type trunk
[RouterA-Ethernet2/0/4] port trunk allow-pass vlan 10
[RouterA-Ethernet2/0/4] quit
```

步骤2 配置DHCP Snooping功能

全局使能DHCP Snooping功能。

```
[RouterA] dhcp enable
[RouterA] dhcp snooping enable
```

在VLAN 10内使能DHCP Snooping功能。

```
[RouterA] vlan 10
[RouterA-vlan10] dhcp snooping enable
[RouterA-vlan10] quit
```

配置接口Eth2/0/4为DHCP Snooping信任接口。

```
[RouterA] interface ethernet 2/0/4
[RouterA-Ethernet2/0/4] dhcp snooping trusted
[RouterA-Ethernet2/0/4] quit
```

步骤3 配置静态绑定表

```
[RouterA] user-bind static ip-address 10.0.0.2 mac-address 00e0-fc01-0101 interface ethernet 2/0/3
vlan 10
```

步骤4 使能动态ARP检测功能和动态ARP检测丢弃报文告警功能

以Eth2/0/1为例，Eth2/0/1、Eth2/0/2和Eth2/0/3的配置与Eth2/0/1相同，此处省略。

```
[RouterA] interface ethernet 2/0/1
[RouterA-Ethernet2/0/1] arp anti-attack check user-bind enable
[RouterA-Ethernet2/0/1] arp anti-attack check user-bind alarm enable
[RouterA-Ethernet2/0/1] quit
```

步骤5 验证配置结果

执行命令**display arp anti-attack check user-bind interface**，查看各接口下动态ARP检测的配置信息，以Eth2/0/1为例。

```
[RouterA] display arp anti-attack check user-bind interface ethernet 2/0/1
arp anti-attack check user-bind enable
arp anti-attack check user-bind alarm enable
ARP packet drop count = 966
```

由显示信息可知，接口Eth2/0/1下产生了ARP报文丢弃计数，表明防ARP中间人攻击功能已经生效。

当在各接口下多次执行命令**display arp anti-attack check user-bind interface**时，管理员可根据显示信息中“ARP packet drop count”字段值的变化来了解ARP中间人攻击频率和范围。

----结束

配置文件

RouterA的配置文件：

```
#
sysname RouterA
```

```
#
vlan batch 10
#
dhcp enable
#
dhcp snooping enable
user-bind static ip-address 10.0.0.2 mac-address 0001-0001-0001 interface Ethernet2/0/3 vlan 10
#
vlan 10
  dhcp snooping enable
#
interface Ethernet2/0/1
  port link-type access
  port default vlan 10
  arp anti-attack check user-bind enable
  arp anti-attack check user-bind alarm enable
#
interface Ethernet2/0/2
  port link-type access
  port default vlan 10
  arp anti-attack check user-bind enable
  arp anti-attack check user-bind alarm enable
#
interface Ethernet2/0/3
  port link-type access
  port default vlan 10
  arp anti-attack check user-bind enable
  arp anti-attack check user-bind alarm enable
#
interface Ethernet2/0/4
  port link-type trunk
  port trunk allow-pass vlan 10
  dhcp snooping trusted
#
return
```

11.9 ARP 安全 FAQ

11.9.1 使能 ARP 网关冲突后，使用某 MAC 发送网关冲突 ARP 报文，再使用该 MAC 发送转发流量为何不通

ARP网关冲突功能检测到冲突的ARP报文后，会将具有该源MAC的报文转发全部禁止，三分钟后放开限制。

11.9.2 用户发送相同源 IP 的 ARP 请求报文，为何有时只能收到 5pps 速率的回应报文

设备对相同源IP的ARP报文做了默认限速，防止产生ARP攻击，缺省限速值为5pps。

11.9.3 如何配置防止内网攻击

内网攻击主要是一些二层协议报文的攻击，最主要攻击手段就是利用ARP对设备进行攻击，影响用户上网，因此一般的内网防攻击，主要就是ARP防攻击，主要防攻击手段有：

- 严格学习ARP表项，是指设备只学习自己发送的ARP请求报文的应答报文：使用命令 **arp learning strict**，配置全局严格学习ARP表项。

- ARP网关冲突的配置，防止用户冒充网关，导致其他用户无法上网：使用命令**arp anti-attack gateway-duplicate enable**，配置全局使能ARP网关冲突防攻击功能。
- 为防止用户的报文不能正常的转发到网关或者被恶意攻击者窃听，设备可以配置发送免费ARP报文，定时更新用户ARP表项的网关MAC地址：使用命令**arp gratuitous-arp send enable**，配置全局使能发送免费ARP报文的功能。默认90s发送一次。

说明

如果启用了过多类似的安全措施，可能会影响设备性能。

12 端口安全配置

12.1 端口安全简介

介绍端口安全的定义和目的。

12.2 端口安全原理描述

通过介绍安全MAC地址的分类和超过安全MAC地址限制数后的保护动作，说明端口安全的实现原理。

12.3 端口安全应用场景

介绍端口安全常见的应用场景。

12.4 端口安全配置注意事项

介绍端口安全的配置注意事项。

12.5 端口安全缺省配置

介绍端口安全的缺省配置。

12.6 配置端口安全

12.7 端口安全配置举例

结合组网需求、配置思路来了解实际网络中端口安全的应用场景，并提供配置文件。

12.1 端口安全简介

介绍端口安全的定义和目的。

端口安全（Port Security）通过将接口学习到的动态MAC地址转换为安全MAC地址（包括安全动态MAC和Sticky MAC），阻止除安全MAC和静态MAC之外的主机通过本接口和设备通信，从而增强设备的安全性。

12.2 端口安全原理描述

通过介绍安全MAC地址的分类和超过安全MAC地址限制数后的保护动作，说明端口安全的实现原理。

安全 MAC 地址的分类

安全MAC地址分为：安全动态MAC与Sticky MAC。

表 12-1 安全 MAC 地址的说明

类型	定义	特点
安全动态MAC地址	使能端口安全而未使能Sticky MAC功能时转换的MAC地址。	设备重启后表项会丢失，需要重新学习。缺省情况下不会被老化，只有在配置安全MAC的老化时间后才可以被老化。
Sticky MAC地址	使能端口安全后又同时使能Sticky MAC功能后转换到的MAC地址。	不会被老化，手动保存配置后重启设备不会丢失。

未使能端口安全功能时，设备的MAC地址表项可通过动态学习或静态配置。当某个接口使能端口安全功能后，该接口上之前学习到的动态MAC地址表项会被删除，之后学习到的MAC地址将变为安全动态MAC地址，此时该接口仅允许匹配安全MAC地址或静态MAC地址的报文通过。若接着使能Sticky MAC功能，安全动态MAC地址表项将转化为Sticky MAC表项，之后学习到的MAC地址也变为Sticky MAC地址。直到安全MAC地址数量达到限制，将不再学习MAC地址，并对接口或报文采取配置的保护动作。

超过安全 MAC 地址限制数后的动作

接口上安全MAC地址数达到限制后，如果收到源MAC地址不存在的报文，端口安全则认为有非法用户攻击，就会根据配置的动作对接口做保护处理。缺省情况下，保护动作是丢弃该报文并上报告警。

表 12-2 端口安全的保护动作

动作	实现说明
restrict	丢弃源MAC地址不存在的报文并上报告警。推荐使用restrict动作。 说明 设备收到非法MAC地址的报文时，每30s至少告警1次，至多告警2次。
protect	只丢弃源MAC地址不存在的报文，不上报告警。
shutdown	接口状态被置为error-down，并上报告警。 默认情况下，接口关闭后不会自动恢复，只能由网络管理人员执行undo shutdown命令手动恢复，也可以在接口视图下执行restart命令重启接口。

12.3 端口安全应用场景

介绍端口安全常见的应用场景。

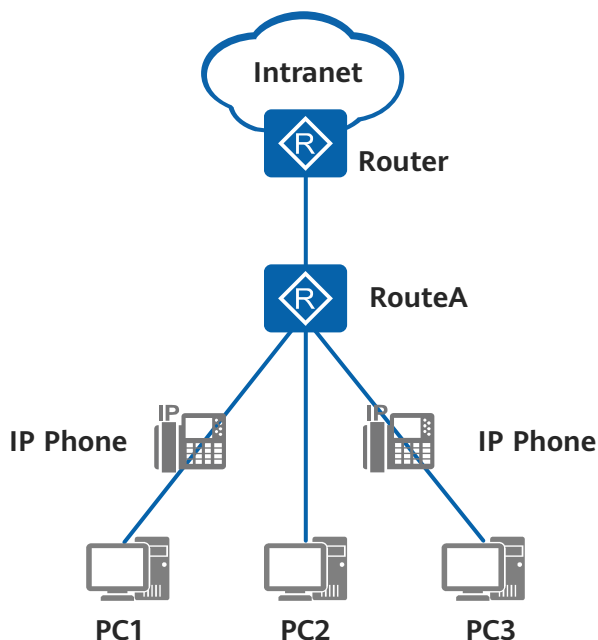
端口安全经常使用在以下几种场景：

- 应用在接入层设备，通过配置端口安全可以防止仿冒用户从其他端口攻击。
- 应用在汇聚层设备，通过配置端口安全可以控制接入用户的数量。

接入层使用场景

如图12-1，用户PC1和PC3通过IP Phone接入RouterA设备，用户PC2直接接入设备RouterA，为了保证接入设备安全性，防止非法用户攻击，可以在接入设备RouterA的接口上配置端口安全功能。

图 12-1 端口安全使用在接入设备的组网场景



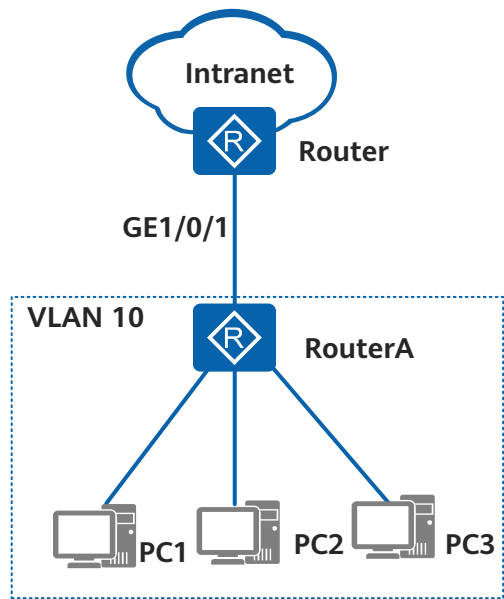
说明

- 如果接入用户变动比较频繁，可以通过端口安全把动态MAC地址转换为安全动态MAC地址。这样可以在用户变动时，及时清除绑定的MAC地址表项。
- 如果接入用户变动较少，可以通过端口安全把动态MAC地址转换为Sticky MAC地址。这样在保存配置重启后，绑定的MAC地址表项不会丢失。

汇聚层使用场景

如图12-2，树状组网中，多个用户通过RouterA和汇聚层设备Router进行通信。为了保证汇聚设备的安全性，控制接入用户的数量，可以在汇聚设备Router配置端口安全功能，同时指定安全MAC地址的限制数。

图 12-2 端口安全使用在汇聚层设备的组网场景



12.4 端口安全配置注意事项

介绍端口安全的配置注意事项。

涉及网元

无需其他网元配合。

License 支持

端口安全是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

仅8FE1GE单板上的LAN侧接口支持端口安全功能。

特性依赖和限制

端口安全默认安全MAC地址的限制数是1个，即只能学习一个MAC地址表项，请根据组网需求正确配置安全MAC地址的限制数。

12.5 端口安全缺省配置

介绍端口安全的缺省配置。

表 12-3 端口安全的缺省配置

参数	缺省值
端口安全功能	未使能

参数	缺省值
端口学习的安全MAC地址数	1个
达到安全MAC地址数后的保护动作	restrict：丢弃源MAC地址不存在的报文并上报告警
安全MAC老化时间	不老化

12.6 配置端口安全

端口安全（Port Security）功能将设备接口学习到的MAC地址变为安全MAC地址（包括安全动态MAC和Sticky MAC），可以阻止除安全MAC和静态MAC之外的主机通过本接口和路由器通信，从而增强设备安全性。

前置任务

在配置端口安全之前，需完成以下任务：

- 关闭基于接口的MAC地址学习限制功能。
- 关闭配置的MUX VLAN功能。
- 关闭MAC认证功能。
- 关闭802.1x认证功能。
- 关闭DHCP Snooping的MAC安全功能。

12.6.1 配置安全 MAC 功能

背景信息

在对接入用户的安全性要求较高的网络中，可以配置端口安全功能，将接口学习到的MAC地址转换为安全MAC地址，接口学习的最大MAC数量达到上限后不再学习新的MAC地址，只允许这些MAC地址和设备通信。这样可以阻止其他非信任用户通过本接口和路由器通信，提高设备与网络的安全性。

操作步骤

- 步骤1** 执行命令`system-view`，进入系统视图。
- 步骤2** 执行命令`interface interface-type interface-number`，进入接口视图。
- 步骤3** 执行命令`port-security enable`，使能端口安全功能。
- 缺省情况下，未使能端口安全功能。
- 步骤4** 执行命令`port-security max-mac-num max-number`，配置端口安全动态MAC学习限制数量。
- 缺省情况下，接口学习的安全MAC地址限制数量为1。

 说明

- 端口默认限制数为1，如果有多个用户通过一个接口接入，请使用**port-security max-mac-num**修改限制数。
- 如果用户PC使用IP Phone连接设备，MAC地址学习限制数请配置为3个。因为IP Phone需要占用两个MAC地址表项，PC需要占用一个MAC地址表项。其中IP Phone占用的两个MAC地址表项的VLAN不同，一个VLAN用来传输语音报文，一个VLAN用来传输数据报文。

步骤5 （可选）执行命令**port-security protect-action { protect | restrict | shutdown }**，配置端口安全保护动作。

缺省情况下，端口安全保护动作为**restrict**。

步骤6 （可选）执行命令**port-security aging-time time**，配置接口学习到的安全动态MAC地址的老化时间。

缺省情况下，接口学习的安全动态MAC地址不老化。

----结束

后续处理

- 查看安全MAC地址。
执行命令**display mac-address security [vlan vlan-id | interface-type interface-number]**，查看安全动态MAC表项。
- 接口上安全MAC地址数达到限制后，如果收到源MAC地址不存在的报文，端口安全则认为有非法用户攻击，就会根据配置的动作对接口做保护处理。端口安全保护动作有以下三种：**restrict**、**protect**和**shutdown**。

表 12-4 端口安全的保护动作

动作	实现说明
restrict	丢弃源MAC地址不存在的报文并上报告警。推荐使用restrict动作。 说明 设备收到非法MAC地址的报文时，每30s至少告警1次，至多告警2次。
protect	只丢弃源MAC地址不存在的报文，不上报告警。
shutdown	接口状态被置为error-down，并上报告警。 默认情况下，接口关闭后不会自动恢复，只能由网络管理人员执行 undo shutdown 命令手动恢复，也可以在接口视图下执行 restart 命令重启接口。

12.6.2 配置 Sticky MAC 功能

背景信息

在对接入用户的安全性要求较高的网络中，可以配置端口安全功能，将接口学习到的MAC地址转换为安全MAC地址，接口学习的最大MAC数量达到上限后不再学习新的MAC地址，只允许这些MAC地址和设备通信。这样可以阻止其他非信任用户通过本接口和路由器通信，提高设备与网络的安全性。

Sticky MAC功能一般使用在终端用户变更较少的网络中。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface interface-type interface-number**，进入接口视图。

步骤3 执行命令**port-security enable**，使能端口安全功能。

缺省情况下，未使能端口安全功能。

步骤4 执行命令**port-security mac-address sticky**，使能接口Sticky MAC功能。

缺省情况下，接口未使能Sticky MAC功能。

步骤5 执行命令**port-security max-mac-num max-number**，配置接口Sticky MAC学习限制数量。

使能接口Sticky MAC功能后，缺省情况下，接口学习的MAC地址限制数量为1。

说明

- 端口默认限制数为1，如果有多个用户通过一个接口接入，请使用**port-security max-mac-num**修改限制数。
- 如果用户PC使用IP Phone连接设备，MAC地址学习限制数请配置为3个。因为IP Phone需要占用两个MAC地址表项，PC需要占用一个MAC地址表项。其中IP Phone占用的两个MAC地址表项的VLAN不同，一个VLAN用来传输语音报文，一个VLAN用来传输数据报文。

步骤6 （可选）执行命令**port-security protect-action { protect | restrict | shutdown }**，配置端口安全保护动作。

缺省情况下，端口安全保护动作为**restrict**。

步骤7 （可选）执行命令**port-security mac-address sticky mac-address vlan vlan-id**，手动配置一条**sticky-mac**表项。

说明

- 接口使能Sticky MAC功能，安全动态MAC地址表项将转化为Sticky MAC地址，之后学习到的MAC地址也变为Sticky MAC地址。
- 接口使能Sticky MAC功能，即使配置了**port-security aging-time**，Sticky MAC也不会被老化。
- Sticky MAC地址表项，保存后重启设备不丢弃。

----结束

后续处理

- 执行命令**display mac-address sticky [vlan vlan-id | interface-type interface-number]**，查看Sticky MAC表项。
- 接口上安全MAC地址数达到限制后，如果收到源MAC地址不存在的报文，端口安全则认为有非法用户攻击，就会根据配置的动作对接口做保护处理。端口安全保护动作有以下三种：**restrict**、**protect**和**shutdown**。

表 12-5 端口安全的保护动作

动作	实现说明
restrict	丢弃源MAC地址不存在的报文并上报告警。推荐使用restrict动作。 说明 设备收到非法MAC地址的报文时，每30s至少告警1次，至多告警2次。
protect	只丢弃源MAC地址不存在的报文，不上报告警。
shutdown	接口状态被置为error-down，并上报告警。 默认情况下，接口关闭后不会自动恢复，只能由网络管理人员执行 undo shutdown 命令手动恢复，也可以在接口视图下执行 restart 命令重启接口。

12.7 端口安全配置举例

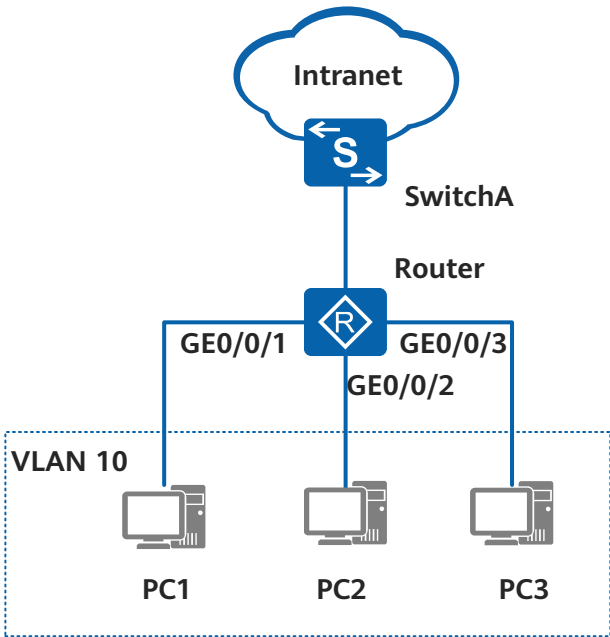
结合组网需求、配置思路来了解实际网络中端口安全的应用场景，并提供配置文件。

12.7.1 配置端口安全示例

组网需求

如图12-3所示，用户PC1、PC2、PC3通过接入设备连接公司网络。为了提高用户接入的安全性，将接入设备Router的接口使能端口安全功能，并且设置接口学习MAC地址数的上限为接入用户数，这样其他外来人员使用自己带来的PC无法访问公司的网络。

图 12-3 配置端口安全示例组网图



配置思路

采用如下的思路配置端口安全：

1. 配置VLAN，实现二层转发功能。
2. 配置端口安全功能，实现学习到的MAC地址表项不老化。

操作步骤

步骤1 在Router上创建VLAN，并把接口加入VLAN。

创建VLAN。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan 10
[Router-vlan10] quit
```

接口GE0/0/1加入VLAN10。接口GE0/0/2和GE0/0/3的配置与接口GE0/0/1相同，不再赘述。

```
[Router] interface gigabitethernet 0/0/1
[Router-GigabitEthernet0/0/1] port link-type access
[Router-GigabitEthernet0/0/1] port default vlan 10
[Router-GigabitEthernet0/0/1] quit
```

步骤2 配置GE0/0/1接口的端口安全功能。

使能接口Sticky MAC功能，同时配置MAC地址限制数。接口GE0/0/2和GE0/0/3的配置与接口GE0/0/1相同，不再赘述。

```
[Router] interface gigabitethernet 0/0/1
[Router-GigabitEthernet0/0/1] port-security enable
[Router-GigabitEthernet0/0/1] port-security mac-address sticky
[Router-GigabitEthernet0/0/1] port-security max-mac-num 1
```

说明

- 端口默认限制数为1，如果有多个用户通过一个接口接入，请使用port-security max-mac-num修改限制数。
- 如果用户PC使用IP Phone连接设备，MAC地址学习限制数请配置为3个。因为IP Phone需要占用两个MAC地址表项，PC需要占用一个MAC地址表项。其中IP Phone占用的两个MAC地址表项的VLAN不同，一个VLAN用来传输语音报文，一个VLAN用来传输数据报文。

步骤3 验证配置结果。

将PC1、PC2、PC3换成其他设备，无法访问公司网络。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10
#
interface GigabitEthernet0/0/1
port link-type access
port default vlan 10
port-security enable
```

```
port-security mac-address sticky
#
interface GigabitEthernet0/0/2
port link-type access
port default vlan 10
port-security enable
port-security mac-address sticky
#
interface GigabitEthernet0/0/3
port link-type access
port default vlan 10
port-security enable
port-security mac-address sticky
#
return
```

13 DHCP Snooping 配置

- [13.1 DHCP Snooping简介](#)
- [13.2 DHCP Snooping原理描述](#)
- [13.3 DHCP Snooping应用场景](#)
- [13.4 DHCP Snooping配置注意事项](#)
- [13.5 DHCP Snooping缺省配置](#)
- [13.6 配置DHCP Snooping的基本功能](#)
- [13.7 配置DHCP Snooping的攻击防范功能](#)
- [13.8 配置在DHCP报文中添加Option82字段](#)
- [13.9 配置通过LDRA功能感知用户位置](#)
- [13.10 配置在DHCPv6报文中添加Option18或Option37字段](#)
- [13.11 维护DHCP Snooping](#)
- [13.12 DHCP Snooping配置举例](#)
- [13.13 DHCP Snooping常见配置错误](#)
- [13.14 DHCP Snooping FAQ](#)

13.1 DHCP Snooping 简介

定义

DHCP Snooping是DHCP（Dynamic Host Configuration Protocol）的一种安全特性，用于保证DHCP客户端从合法的DHCP服务器获取IP地址，并记录DHCP客户端IP地址与MAC地址等参数的对应关系，防止网络上针对DHCP攻击。

目的

目前DHCP协议（RFC2131）在应用的过程中遇到很多安全方面的问题，网络中存在一些针对DHCP的攻击，如DHCP Server仿冒者攻击、DHCP Server的拒绝服务攻击、仿冒DHCP报文攻击等。

为了保证网络通信业务的安全性，可引入DHCP Snooping技术，在DHCP Client和DHCP Server之间建立一道防火墙，以抵御网络中针对DHCP的各种攻击。

受益

- 设备具有防御网络上DHCP攻击的能力，增强了设备的可靠性，保障通信网络的正常运行。
- 为用户提供更安全的网络环境，更稳定的网络服务。

13.2 DHCP Snooping 原理描述

13.2.1 DHCP Snooping 的基本原理

DHCP Snooping能够实现如下基本功能：

信任功能

DHCP Snooping的信任功能，能够保证客户端从合法的服务器获取IP（Internet Protocol）地址。

网络中如果存在私自架设的DHCP Server仿冒者，则可能导致DHCP客户端获取错误的IP地址和网络配置参数，无法正常通信。DHCP Snooping信任功能可以控制DHCP服务器应答报文的来源，以防止网络中可能存在的DHCP Server仿冒者为DHCP客户端分配IP地址及其他配置信息。

DHCP Snooping信任功能将接口分为信任接口和非信任接口：

- 信任接口正常接收DHCP服务器响应的DHCP ACK、DHCP NAK和DHCP Offer报文。
- 非信任接口在接收到DHCP服务器响应的DHCP ACK、DHCP NAK和DHCP Offer报文后，丢弃该报文。

说明

管理员在部署网络时，一般将与合法DHCP服务器直接或间接连接的接口设置为信任接口，其他接口设置为非信任接口，从而保证DHCP客户端只能从合法的DHCP服务器获取IP地址，私自架设的DHCP Server仿冒者无法为DHCP客户端分配IP地址。

分析功能

开启DHCP Snooping功能后，设备能够通过分析DHCP的报文交互过程，生成DHCP Snooping绑定表，绑定表项包括客户端的MAC地址、获取到的IP地址、与DHCP客户端连接的接口及该接口所属的VLAN（Virtual Local Area Network）等信息。

DHCP Snooping绑定表根据DHCP租期进行老化或根据用户释放IP地址时发出的DHCP Release报文自动删除对应表项。

出于安全性的考虑，管理员需要记录用户上网时所用的IP地址，确认用户申请的IP地址和用户使用的主机的MAC地址的对应关系。在设备通过DHCP Snooping功能生成绑定表后，管理员可以方便的记录DHCP用户申请的IP地址与所用主机的MAC地址之间的对应关系。

由于DHCP Snooping绑定表记录了DHCP客户端IP地址与MAC地址等参数的对应关系，故通过对报文与DHCP Snooping绑定表进行匹配检查，能够有效防范非法用户的攻击。

为了保证设备在生成DHCP Snooping绑定表时能够获取到用户MAC等参数，DHCP Snooping功能需应用于二层网络中的接入设备或第一个DHCP Relay上。

13.2.2 DHCP Snooping 支持的 Option82 功能

概述

在传统的DHCP动态分配IP地址过程中，DHCP Server不能够根据DHCP请求报文感知到用户的具体物理位置，以致同一VLAN的用户得到的IP地址所拥有的权限是完全相同的。由于网络管理者不能对同一VLAN中特定的用户进行有效的控制，即不能够控制客户端对网络资源的访问，这将给网络的安全控制提出了严峻的挑战。

RFC 3046定义了DHCP Relay Agent Information Option（Option 82），该选项记录了DHCP Client的位置信息。DHCP Snooping设备或DHCP Relay通过在DHCP请求报文中添加Option82选项，将DHCP Client的精确物理位置信息传递给DHCP Server，从而使得DHCP Server能够为主机分配合适的IP地址和其他配置信息，实现对客户端的安全控制。

Option82包含两个常用子选项Circuit ID和Remote ID。其中Circuit ID子选项主要用来标识客户端所在的VLAN、接口等信息，Remote ID子选项主要用来标识客户端接入的设备，一般为设备的MAC地址。

设备作为DHCP Relay时，使能或未使能DHCP Snooping功能都可支持Option82选项功能，但若设备在二层网络作为接入设备，则必须使能DHCP Snooping功能方可支持Option82功能。

Option82选项仅记录了DHCP用户的精确物理位置信息并通过DHCP请求报文中将该信息发送给DHCP Server。而如果需要对不同的用户部署不同的地址分配或安全策略，则需DHCP Server支持Option82功能并在其上已配置了IP地址分配或安全策略。

Option82选项携带的用户位置信息与DHCP Snooping绑定表记录的用户参数是两个相互独立的概念，没有任何关联。Option82选项携带的用户位置信息是在DHCP用户申请IP地址时（此时用户还未分配到IP地址），由设备添加到DHCP请求报文中。DHCP Snooping绑定表是在设备收到DHCP Server回应的DHCP Ack报文时（此时已为用户分配了IP地址），设备根据DHCP Ack报文信息自动生成。

实现

设备作为DHCP Relay或设备在二层网络作为接入设备并使能DHCP Snooping功能时均可支持Option82功能。使能设备的Option82功能有Insert和Rebuild两种方式，使能方式不同设备对DHCP请求报文的处理也不同。

- Insert方式：当设备收到DHCP请求报文时，若该报文中没有Option82选项，则插入Option82选项；若该报文中含有Option82选项，则判断Option82选项中是否包含remote-id，如果包含，则保持Option82选项不变，如果不包含，则插入remote-id。
- Rebuild方式：当设备收到DHCP请求报文时，若该报文中没有Option82选项，则插入Option82选项；若该报文中含有Option82选项，则删除该Option82选项并插入管理员自己在设备上配置的Option82选项。

对于Insert和Rebuild两种方式，当设备接收到DHCP服务器的响应报文时，处理方式一致。

- DHCP响应报文中含有Option82选项：
 - 如果设备收到的DHCP请求报文中没有Option82选项，则设备将删除DHCP响应报文中的Option82选项，之后转发给DHCP Client。

- 如果设备收到的DHCP请求报文中含有Option82选项，则设备将DHCP响应报文中的Option82选项格式还原为DHCP请求报文中的Option82选项，之后转发给DHCP Client。
- DHCP响应报文不含有Option82选项：直接转发。

13.2.3 DHCPv6 Snooping 支持的 LDRA 功能

概述

RFC 6221定义了轻量级DHCPv6中继代理LDRA（Lightweight DHCPv6 Relay Agent），它是一种在DHCPv6交互报文中插入中继代理选项信息以标示用户位置的规范。

类似于DHCPv4网络中使用的Option82选项，在DHCPv6网络中可以使用LDRA获取用户详细的位置信息。LDRA一般部署在靠近用户的接入设备上。

实现

LDRA工作流程与DHCPv6中继工作流程相似。当接收到用户的DHCPv6请求报文时，部署LDRA功能的设备即会构建Relay-Forward报文并在其中封装用户的位置信息（如用户与设备连接的接口信息等）然后转发给DHCPv6 Server，从而使得DHCPv6 Server能够获取到DHCPv6 Client的物理位置信息进而为用户部署诸如IP地址分配、QoS、接入控制等策略。

如图13-1所示，LDRA详细工作交互过程如下。

图 13-1 LDRA 工作流程图

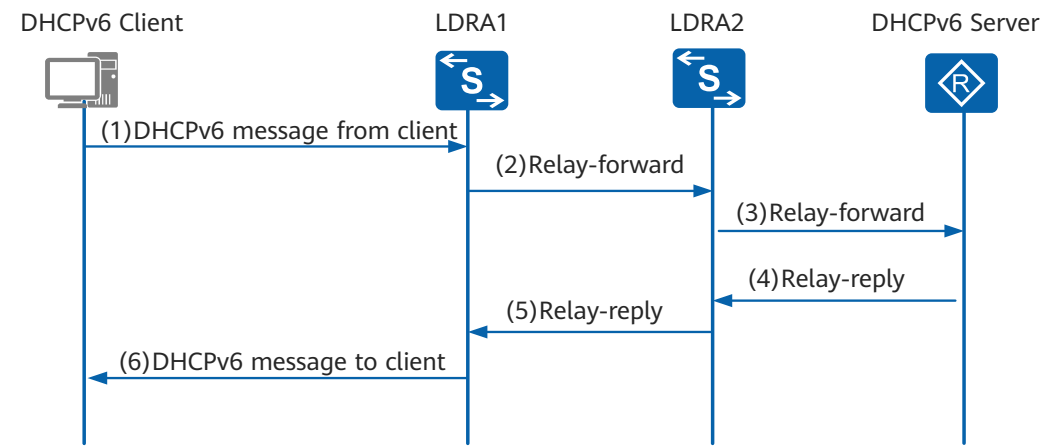


表 13-1 LDRA 报文封装格式

封装流程	报文封装格式
(1) DHCPv6 to LDRA1 Client	DHCPv6 message from client
(2) LDRA1 to LDRA2	RELAY-FORW封装 DHCPv6 message from client LDR1 msg-type hop-count link-address peer-address interface-id remote-id

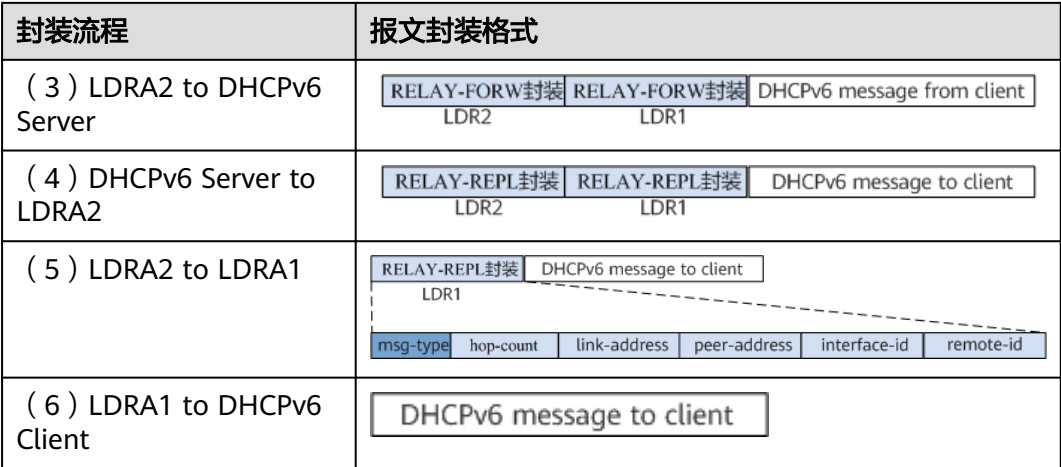


表 13-2 LDRA 报文中各个字段的含义

字段	长度	含义
msg-type	1字节	表示报文的类型，取值为1~13，其中： - Relay-forward Message: RELAY-FORW（12） - Relay-reply Message: RELAY-REPL（13）
hop-count	1字节	中继代理设备数。
link-address	12字节	全局或站点本地地址，服务器使用该地址来标识客户端所在的链路。
peer-address	12字节	相邻的客户端或者中继代理设备的地址。
interface-id	可变	即Option18，记录了客户端在本LDRA的接口位置信息。
remote-id	可变	即Option37，记录了LDRA设备的MAC地址信息。

1. DHCPv6客户端向LDRA设备发送DHCPv6报文。
2. LDRA设备收到客户端的DHCPv6报文后，将其封装在Relay-Forward报文中继消息选项中，同时将用户在本LDRA的位置信息封装在Relay-Forward报文中的interface-id或remote-id中，之后将Relay-Forward报文发送给下一台LDRA设备。
3. 每经过一台LDRA设备，LDRA设备都在DHCPv6报文增加一层DHCPv6 Relay-Forward信息，同时将用户在本LDRA的位置信息封装在Relay-Forward报文中的interface-id和remote-id中。

4. DHCPv6服务器从Relay-Forward报文中解析出DHCPv6客户端的请求以及用户位置信息，之后根据用户位置信息为DHCPv6客户端选取IPv6地址和其他配置参数，构造应答消息，将应答消息封装在Relay-Reply报文中，并发送给LDRA设备。
5. LDRA设备从Relay-Reply报文中去掉本层LDRA的Relay-reply封装，并将报文传递到下一跳LDRA设备。
6. LDRA设备从Relay-Reply报文中解析出DHCPv6服务器的应答，转发给DHCPv6客户端。DHCPv6客户端根据应答报文获取到DHCPv6服务器地址，后续从该服务器获取IPv6地址和其他网络配置参数。

13.2.4 DHCPv6 Snooping 支持的 option18 与 option37 功能

Option18与Option37选项功能类似于Option82。Option82用于插入DHCPv4报文中，而对于DHCPv6报文则需插入Option18与Option37选项用于记录DHCPv6 Client的位置信息。

说明

设备必须使能DHCPv6 snooping功能方可支持Option18与Option37选项功能。

13.3 DHCP Snooping 应用场景

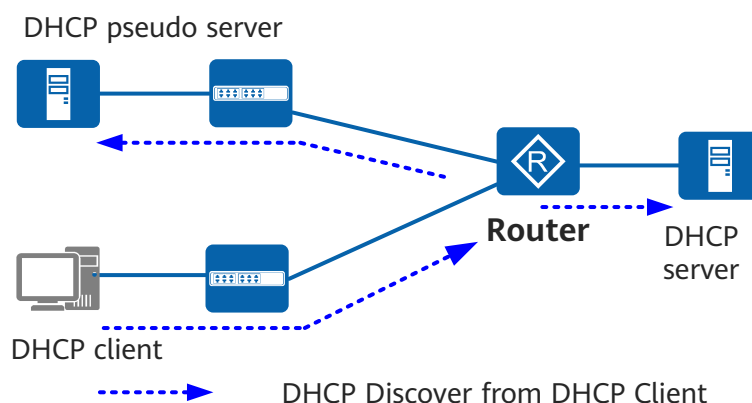
13.3.1 防止 DHCP Server 仿冒者攻击

攻击原理

由于DHCP Server和DHCP Client之间没有认证机制，所以如果在网络上随意添加一台DHCP服务器，它就可以为客户端分配IP地址以及其他网络参数。如果该DHCP服务器为用户分配错误的IP地址和其他网络参数，将会对网络造成非常大的危害。

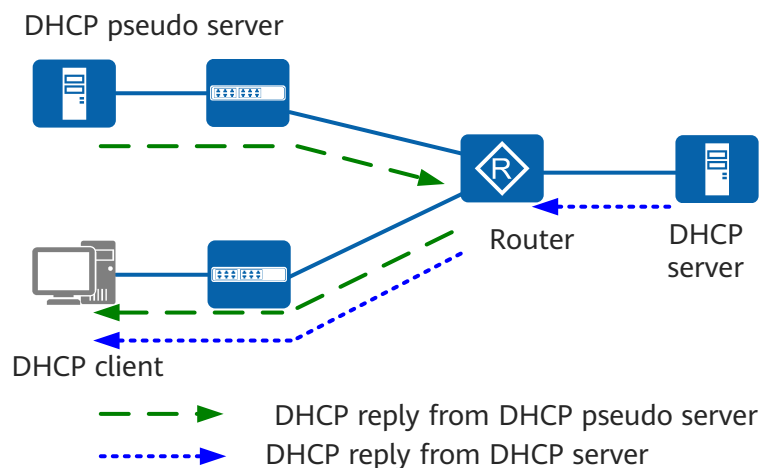
如图13-2所示，DHCP Discover报文是以广播形式发送，无论是合法的DHCP Server，还是非法的DHCP Server都可以接收到DHCP Client发送的DHCP Discover报文。

图 13-2 DHCP Client 发送 DHCP Discover 报文示意图



如果此时DHCP Server仿冒者回应给DHCP Client仿冒信息，如错误的网关地址、错误的DNS（Domain Name System）服务器、错误的IP等信息，如图13-3所示。DHCP Client将无法获取正确的IP地址和相关信息，导致合法客户无法正常访问网络或信息安全受到严重威胁。

图 13-3 DHCP Server 仿冒者攻击示意图

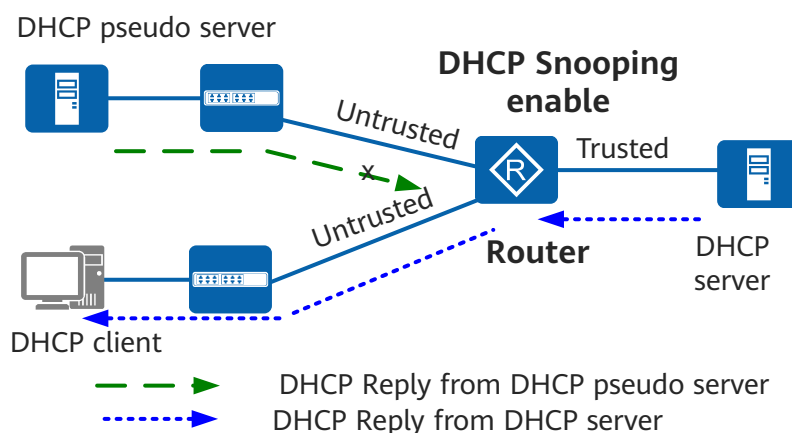


解决方法

为了防止DHCP Server仿冒者攻击，可配置设备接口的“信任（Trusted）/非信任（Untrusted）”工作模式。

将与合法DHCP服务器直接或间接连接的接口设置为信任接口，其他接口设置为非信任接口。此后，从“非信任（Untrusted）”接口上收到的DHCP回应报文将被直接丢弃，这样可以有效防止DHCP Server仿冒者的攻击。如图13-4所示。

图 13-4 Trusted/Untrusted 工作模式示意图



13.3.2 防止仿冒 DHCP 报文攻击

攻击原理

已获取到IP地址的合法用户通过向服务器发送DHCP Request或DHCP Release报文用以续租或释放IP地址。如果攻击者冒充合法用户不断向DHCP Server发送DHCP Request报文来续租IP地址，会导致这些到期的IP地址无法正常回收，以致一些合法用户不能获得IP地址；而若攻击者仿冒合法用户的DHCP Release报文发往DHCP Server，将会导致用户异常下线。

解决方法

为了有效的防止仿冒DHCP报文攻击，可利用DHCP Snooping绑定表的功能。设备通过将DHCP Request续租报文和DHCP Release报文与绑定表进行匹配操作能够有效的

判别报文是否合法（主要是检查报文中的VLAN、IP、MAC、接口信息是否匹配动态绑定表），若匹配成功则转发该报文，匹配不成功则丢弃。

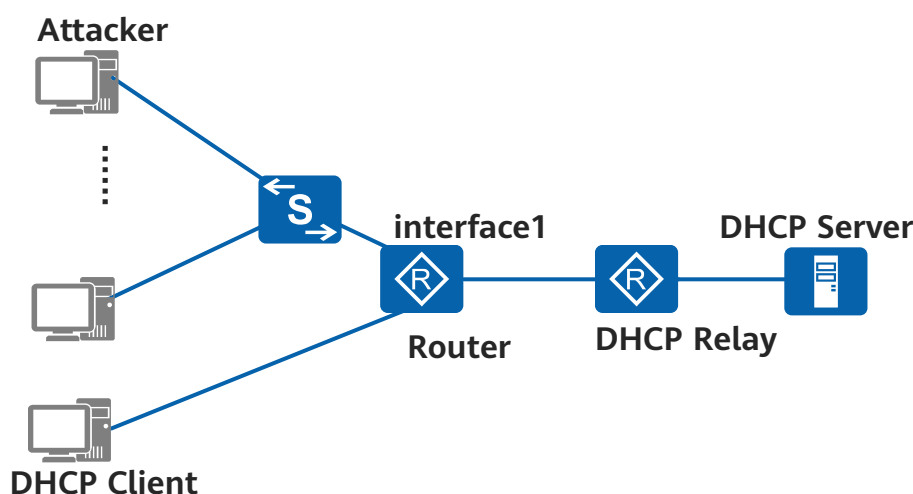
13.3.3 防止 DHCP Server 服务拒绝攻击

攻击原理

如图13-5所示，若设备接口interface1下存在大量攻击者恶意申请IP地址，会导致DHCP Server中IP地址快速耗尽而不能为其他合法用户提供IP地址分配服务。

另一方面，DHCP Server通常仅根据DHCP Request报文中的CHADDR（Client Hardware Address）字段来确认客户端的MAC地址。如果某一攻击者通过不断改变CHADDR字段向DHCP Server申请IP地址，同样将会导致DHCP Server上的地址池被耗尽，从而无法为其他正常用户提供IP地址。

图 13-5 DHCP Server 服务拒绝攻击示意图



解决方法

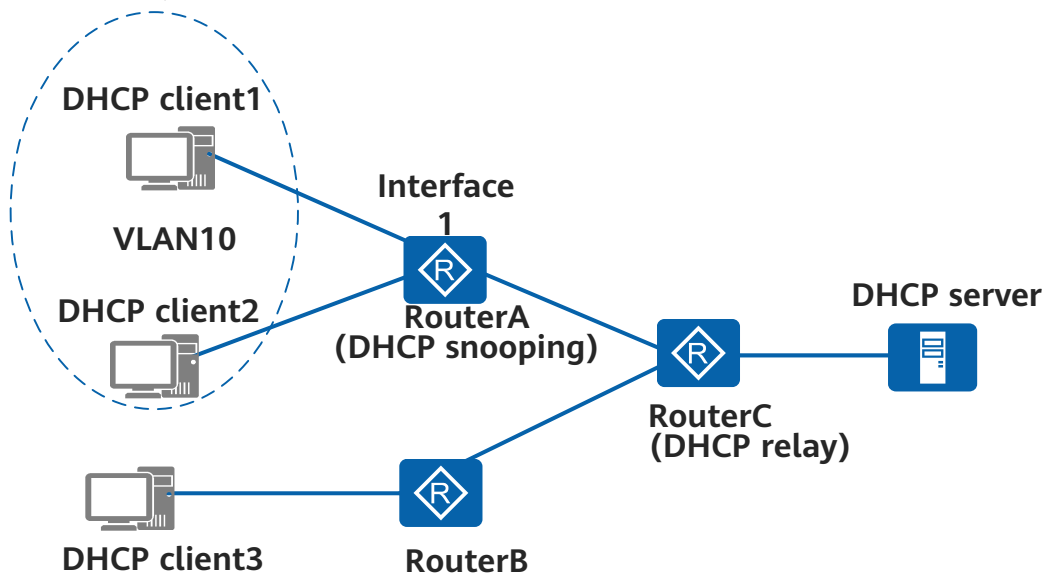
为了抑制大量DHCP用户恶意申请IP地址，在使能设备的DHCP Snooping功能后，可配置设备或接口允许接入的最大DHCP用户数，当接入的用户数达到该值时，则不再允许任何用户通过此设备或接口成功申请到IP地址。

而对通过改变DHCP Request报文中的CHADDR字段方式的攻击，可使能设备检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能，此后设备将检查上送的DHCP Request报文中的帧头MAC地址是否与CHADDR值相等，相等则转发，否则丢弃。

13.3.4 Option82 的典型应用

Option 82（DHCP Relay Agent Information Option）称为中继代理信息选项，该选项记录了DHCP Client的位置信息。DHCP Snooping设备或DHCP Relay通过在DHCP请求报文中添加Option82选项，将DHCP Client的位置信息传递给DHCP Server，从而使得DHCP Server能够为主机分配合适的IP地址和其他配置信息，并实现对客户端的安全控制。

图 13-6 Option82 应用组网图



如图13-6所示，用户通过DHCP方式获取IP地址。在管理员组建该网络时需要控制接口interface1下用户对网络资源的访问以提高网络的安全性。

在传统的DHCP动态分配IP地址过程中，DHCP Server是无法区分同一VLAN内的不同用户的，以致同一VLAN内的用户得到的IP地址所拥有的权限是完全相同的。

为实现上述目的，管理员在使能RouterA的DHCP Snooping功能之后可使其Option82功能。之后RouterA在接收到用户申请IP地址发送的DHCP请求报文时，将会在报文中插入Option82选项，以标注用户的精确位置信息，譬如MAC地址、所属VLAN、所连接的接口号等参数。DHCP Server在接收到携带有Option82选项的DHCP请求报文后，即可通过Option82选项的内容获悉到用户的精确物理位置进而根据其上已部署的IP地址分配策略或其他安全策略为用户分配合适的IP地址和其他配置信息。

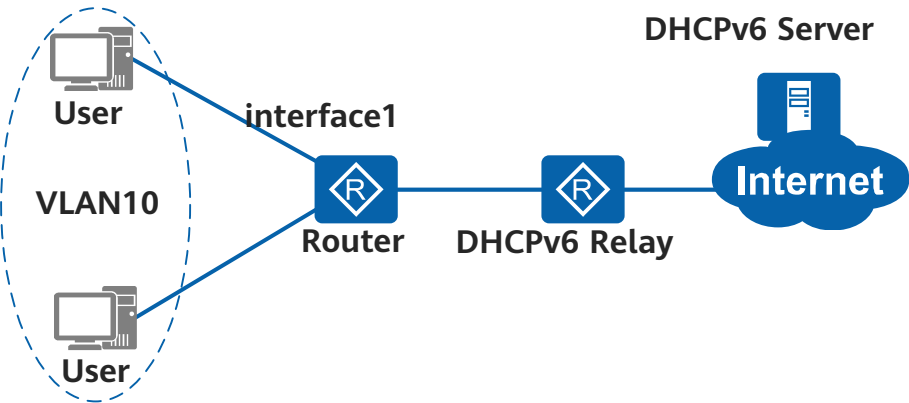
Option82选项仅记录了DHCP用户的精确物理位置信息并通过DHCP请求报文中将该信息发送给DHCP Server。而如果需要对不同的用户部署不同的地址分配或安全策略，则需DHCP Server支持Option82功能并在其上已配置了IP地址分配或安全策略。

13.3.5 通过 LDRA 功能感知用户位置信息

LDRA称为轻量级DHCPv6中继代理，该中继代理能够记录用户位置信息并将其发送到DHCPv6 Server，从而使得DHCPv6 Server能够获取到用户详细的物理位置信息，实现对用户客户端部署诸如地址分配、计费、接入控制等策略。

如图13-7所示，用户通过DHCPv6方式获取IPv6地址。在管理员部署该网络时需要限制接口interface1下的用户对网络资源的访问以提高网络的安全性。

图 13-7 LDRA 应用组网图



在传统的DHCPv6动态分配IPv6地址过程中，DHCPv6 Server无法获取到用户详细的物理位置信息，以致不能为interface1接口下的用户部署地址分配、接入控制等策略。

为解决上述问题，管理员在使能Router的DHCP Snooping功能之后，可使其LDRA功能。这样，Router既能够获取用户详细的位置信息并将其发送到DHCPv6 Server。DHCPv6 Server即可根据用户的详细位置信息为其部署地址分配策略或其他安全策略。

LDRA功能仅是记录了DHCPv6用户的详细位置信息并通过RELAY-FORW报文将该信息发送给DHCPv6 Server，对不同的用户部署诸如地址分配、计费、接入控制等策略，由DHCPv6 Server实现。

13.4 DHCP Snooping 配置注意事项

涉及网元

无需其他网元配合。

License 支持

DHCP Snooping是设备的基本特性，无需获得License许可即可应用此功能。

硬件依赖

表 13-3 DHCP Snooping 硬件依赖

系列	特性支持情况
AR300&AR700系列	- 支持DHCP Snooping。 - 仅AR720和AR730支持DHCPv6 Snooping。

对于设备上的单板而言，仅8FE1GE单板支持此功能。

特性依赖和限制

- IPv4 DHCP snooping功能可以在二层接入设备和第一跳DHCPv4 Relay设备上配置；IPv6 DHCP snooping功能可以在二层接入设备和第一跳DHCPv6 Relay设备上配置。当配置DHCP Snooping功能的设备是DHCP中继设备时，不需要配置命令**dhcp snooping trusted**。
- DHCP触发ARP学习功能仅适用于有线用户、无线用户不支持。
- 如果设备使能了DHCP Snooping功能，不能配置2 to 2的VLAN Mapping功能，否则会导致DHCP用户无法上线。

13.5 DHCP Snooping 缺省配置

DHCP Snooping的缺省配置如表13-4所示：

表 13-4 DHCP Snooping 的缺省配置

参数	缺省值
DHCP Snooping功能	未使能
接口的信任状态	非信任
DHCP Snooping用户位置迁移功能	已使能
ARP与DHCP Snooping的联动功能	未使能
DHCP Snooping支持的Option82功能	未使能
对DHCP报文进行绑定表匹配检查的功能	未使能
检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能	未使能
检测DHCP Request报文中GIADDR字段是否非零的功能	未使能

13.6 配置 DHCP Snooping 的基本功能

前置任务

在配置DHCP Snooping的基本功能之前，需要完成以下任务：

- 网络中已完成DHCP功能的部署。

本章节中，**使能DHCP Snooping功能**、**配置接口信任状态**同样适用于DHCPv6 Snooping。

配置流程

配置DHCP Snooping的基本功能需要在设备上进行以下配置。

13.6.1 使能 DHCP Snooping 功能

背景信息

DHCP Snooping是一种DHCP安全特性，在配置DHCP Snooping各安全功能之前需首先使能DHCP Snooping功能。

使能DHCP Snooping功能的顺序是先使能全局下的DHCP Snooping功能，再使能接口或VLAN下的DHCP Snooping功能。

说明

使能DHCP Snooping功能之前，必须已使用命令**dhcp enable**使能了设备的DHCP功能。

为使设备能够获取到用户的绑定表项，在接口或VLAN下使能DHCP Snooping功能之前，需确保已在该接口或VLAN对应的VLANIF口上使能了DHCP Relay或DHCP Server功能。

说明

DHCP Snooping不支持BOOTP协议，而无盘工作站使用BOOTP协议，所以无盘工作站不能通过DHCP Snooping生成动态绑定表。由于IPSG功能和DAI功能是基于绑定表实现的，如果无盘工作站要使用以上功能，需要执行命令**user-bind static**配置静态绑定表。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcp snooping enable [ipv4 | ipv6]**，全局使能DHCP Snooping功能。

缺省情况下，设备全局未使能DHCP Snooping功能。

说明

系统视图下，**dhcp snooping enable**命令是DHCP Snooping相关功能的总开关。执行**undo dhcp snooping enable**命令后，设备上所有DHCP Snooping相关的配置会被删除；再次执行**dhcp snooping enable**命令使能DHCP Snooping功能后，设备上所有DHCP Snooping相关配置将被恢复为缺省配置。

步骤3 使能DHCP Snooping功能，可在系统视图、VLAN视图或接口视图下进行配置。

- 系统视图下：

1. 执行命令**dhcp snooping enable vlan { vlan-id1 [to vlan-id2] }** <1-10>，使能DHCP Snooping功能。

缺省情况下，设备未使能DHCP Snooping功能。

- VLAN视图或接口视图下：

1. 执行命令**vlan vlan-id**，进入VLAN视图；或执行命令**interface interface-type interface-number**，进入连接用户的接口视图。
2. 执行命令**dhcp snooping enable**，使能接口或VLAN下的DHCP Snooping功能。

缺省情况下，设备未使能DHCP Snooping功能。

在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCP报文命令功能生效；在接口下执行该命令，则对该接口下的所有DHCP报文命令功能生效。

若使用命令**dot1q termination vid**配置了子接口dot1q封装的单层VLAN ID，则不能在该VLAN内使能DHCP Snooping功能。

----结束

13.6.2 配置接口信任状态

背景信息

为使DHCP客户端能通过合法的DHCP服务器获取IP地址，需将与管理员信任的DHCP服务器直接或间接连接的设备接口设置为信任接口，其他接口设置为非信任接口。从而保证DHCP客户端只能从合法的DHCP服务器获取IP地址，私自架设的DHCP Server仿冒者无法为DHCP客户端分配IP地址。

在连接用户的接口或VLAN下使能DHCP Snooping功能之后，需将连接DHCP服务器的接口配置为“信任”模式，两者同时生效设备即能够生成DHCP Snooping动态绑定表。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置接口为“信任”状态，可在接口视图、VLAN视图下执行。

- 接口视图下：

- 执行命令**interface interface-type interface-number**，进入接口视图。
- 执行命令**dhcp snooping trusted**，配置接口为“信任”接口。

缺省情况下，接口的状态为“非信任”状态。

- VLAN视图下：

- 执行命令**vlan vlan-id**，进入VLAN视图。
- 执行命令**dhcp snooping trusted interface interface-type interface-number**，配置接口为“信任”接口。

缺省情况下，接口的状态为“非信任”状态。

在VLAN视图下执行此命令，则命令功能仅对加入该VLAN的接口收到的属于此VLAN的DHCP报文生效；在接口下执行该命令，则命令功能对该接口接收到的所有DHCP报文生效。

----结束

13.6.3 （可选）使能 DHCP Snooping 用户位置迁移功能

背景信息

在移动应用场景中，若某一用户由接口A上线后，然后切换到接口B，这时为了让用户能够上线，需要使能DHCP Snooping用户位置迁移功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcp snooping user-transfer enable**，使能DHCP Snooping用户位置迁移功能。

缺省情况下，已使能DHCP Snooping用户位置迁移功能。

----结束

13.6.4 （可选）配置 ARP 与 DHCP Snooping 的联动功能

背景信息

DHCP Snooping设备在收到DHCP用户发出的DHCP Release报文时将会删除该用户对应的绑定表项，但若用户发生了异常下线而无法发出DHCP Release报文时，DHCP Snooping设备将不能够及时的删除该DHCP用户对应的绑定表。

使能ARP与DHCP Snooping的联动功能，如果DHCP Snooping表项中的IP地址对应的ARP表项达到老化时间，则DHCP Snooping设备会对该IP地址进行ARP探测，如果在规定的探测次数内探测不到用户，设备将删除用户对应的ARP表项。之后，设备将会再次按规定的探测次数对该IP地址进行ARP探测，如果最后仍不能够探测到用户，则设备将会删除该用户对应的绑定表项。

说明

使用ARP与DHCP Snooping的联动功能之前，需要保证设备上具有与客户端同网段的IP地址用于ARP探测。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp dhcp-snooping-detect enable**，使能ARP与DHCP Snooping的联动功能。

缺省情况下，未使能ARP与DHCP Snooping的联动功能。

----结束

13.6.5 （可选）配置丢弃 GIADDR 字段非零的 DHCP 报文

背景信息

DHCP报文中的GIADDR（Gateway Ip Address）字段记录了DHCP报文经过的第一个DHCP Relay的IP地址，当客户端发出DHCP请求时，如果服务器和客户端不在同一个网段，那么第一个DHCP Relay在将DHCP请求报文转发给DHCP服务器时，会把自己的IP地址填入此字段，DHCP服务器会根据此字段来判断出客户端所在的网段地址，从而选择合适的地址池，为客户端分配该网段的IP地址。

在为了保证设备在生成DHCP Snooping绑定表时能够获取到用户MAC等参数，DHCP Snooping功能需应用于二层网络中的接入设备或第一个DHCP Relay上。故DHCP Snooping设备接收到的DHCP报文中GIADDR字段必然为零，若不为零则该报文为非法报文，设备需丢弃此类报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 使能检测DHCP Request报文中GIADDR字段是否非零的功能，可在VLAN视图或接口视图下进行配置。

1. 执行命令**vlan *vlan-id***, 进入VLAN视图; 或执行命令**interface *interface-type* *interface-number***, 进入接口视图。
2. 执行命令**dhcp snooping check dhcp-giaddr enable**, 使能检测DHCP Request报文中GIADDR字段是否非零的功能。

缺省情况下, 未使能检测DHCP Request报文中GIADDR字段是否非零的功能。

在VLAN视图下执行此命令, 则对设备所有接口接收到的属于该VLAN的DHCP报文命令功能生效; 在接口下执行该命令, 则对该接口下的所有DHCP报文命令功能生效。

----结束

13.6.6 （可选）配置 DHCPv6 Snooping 探测 confirm-client 是否在线功能

背景信息

confirm-client指通过DHCPv6 Confirm报文生成绑定表的客户端, 当客户端重新上线时, 会发送DHCPv6 Confirm报文。

DHCPv6 Snooping在用户侧端口收到DHCPv6 Confirm报文会生成DHCPv6 Snooping绑定表。由于DHCPv6 Confirm报文没有携带有效租期, 当confirm-client离线时, 绑定表无法及时老化删除, 占用了表项规格, 可能导致新用户无法正常上线。

开启探测confirm-client是否在线功能后, DHCPv6 Snooping会周期性发送DAD类型的NS报文探测用户是否在线, 及时删除下线的confirm-client的DHCPv6 Snooping表项。

操作步骤

步骤1 执行命令**system-view**, 进入系统视图。

步骤2 执行命令**dhcpv6 snooping user-bind detect confirm-client enable**, 开启DHCPv6 Snooping探测confirm-client是否在线功能。

缺省情况下, DHCPv6 Snooping探测confirm-client是否在线功能处于开启状态。

步骤3 执行命令**dhcpv6 snooping user-bind detect retransmit *times* interval *interval***, 配置DHCPv6 Snooping探测用户是否在线的DAD NS报文的发送次数和发送时间间隔。

缺省情况下, DHCPv6 Snooping探测用户是否在线的DAD NS报文发送次数为3次, 发送时间间隔为180秒。

----结束

13.6.7 （可选）去使能接口 DHCP Snooping 功能

背景信息

若使能了某一VLAN的DHCP Snooping功能, 则VLAN内所有的接口均使能了DHCP Snooping功能。此时如果需要去使能一特定接口的DHCP Snooping功能, 可使用命令**dhcp snooping disable**去使能特定接口的DHCP Snooping功能。此后该接口下的用户将能正常上线, 但是并不会生成DHCP动态绑定表。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface interface-type interface-number**，进入指定的接口视图。

步骤3 执行命令**dhcp snooping disable**，去使能接口的DHCP Snooping功能。

缺省情况下，接口的DHCP Snooping功能是否使能依赖于是否在该接口或者该接口所在的VLAN下使用**dhcp snooping enable**命令使能DHCP Snooping功能。

----结束

13.6.8 检查 DHCP Snooping 基本功能的配置结果

背景信息

在配置完成DHCP Snooping的基本功能后，可通过命令查看配置信息。

操作步骤

- 执行命令**display dhcp snooping [interface interface-type interface-number | vlan vlan-id]**，查看DHCP Snooping的运行信息。
- 执行命令**display dhcp snooping configuration [vlan vlan-id | interface interface-type interface-number]**，查看DHCP Snooping的配置信息。
- 执行命令**display dhcp snooping user-bind { { interface interface-type interface-number | ip-address ip-address | mac-address mac-address | vlan vlan-id } * | all } [verbose]**，查看DHCP Snooping绑定表信息。
- 执行命令**display dhcpv6 snooping user-bind { { interface interface-type interface-number | ipv6-address ipv6-address | mac-address mac-address | vlan vlan-id } * | all } [verbose]**，查看DHCPv6 Snooping绑定表信息。
- 执行命令**display dhcpv6 snooping user-bind { { interface interface-type interface-number | ipv6-address ipv6-address | mac-address mac-address | vlan vlan-id } * | all } [verbose]**，查看DHCPv6 Snooping绑定表信息。
- 执行命令**display dhcp snooping statistics { global | vlan vlan-id | interface interface-type interface-number }**，查看设备接收到的各类型DHCP报文的统计信息。
- 执行命令**display dhcpv6 snooping statistics**，查看DHCPv6 Snooping统计信息。

----结束

13.7 配置 DHCP Snooping 的攻击防范功能

本章节中，[配置防止仿冒DHCP报文攻击](#)功能、[配置防止DHCP Server服务拒绝攻击](#)中的“步骤2”相关功能同样适用于DHCPv6 Snooping。

前提条件

配置DHCP Snooping的攻击防范功能之前，务必确保已完成DHCP Snooping的基本功能配置。

13.7.1 配置防止 DHCP Server 仿冒者攻击

背景信息

在使能DHCP Snooping功能并配置了接口的信任状态之后，设备将能够保证客户端从合法的服务器获取IP地址，这将能够有效的防止DHCP Server仿冒者攻击。但是此时却不能定位DHCP Server仿冒者的位置，使得网络中仍然存在着安全隐患。

通过配置DHCP Server探测功能，DHCP Snooping设备将会检查并在日志中记录所有DHCP回应报文中携带的DHCP Server地址与接口等信息，此后网络管理员可根据日志来判定网络中是否存在伪DHCP Server进而对网络进行维护。

DHCP Snooping设备缺省只根据MAC地址检查DHCP回应报文识别设备，仅通过MAC地址无法正确识别设备时，执行**dhcp snooping check server-vlan enable**命令后，DHCP Snooping设备根据MAC地址和VLAN信息检查DHCP回应报文识别设备。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcp snooping enable**，使能了设备的DHCP Snooping功能。

步骤3 执行命令**dhcp server detect**，使能DHCP Server探测功能。

缺省情况下，未使能DHCP Server探测功能。

步骤4 （可选）执行命令**dhcp snooping check server-vlan enable**，使能DHCP Snooping设备检查DHCP回应报文携带VLAN信息功能。

缺省情况下，未使能DHCP Snooping设备检查DHCP回应报文携带VLAN信息功能。

----结束

13.7.2 配置防止仿冒 DHCP 报文攻击

背景信息

在DHCP网络环境中，若攻击者仿冒合法用户的DHCP报文发往DHCP服务器，会导致合法用户无法使用该IP地址或异常下线。在生成DHCP Snooping绑定表后，设备可根据绑定表项，对DHCP报文进行匹配检查，只有匹配成功的报文设备才将其转发，否则将丢弃。这将能有效的防止非法用户通过发送伪造DHCP报文冒充合法用户进行续租或释放IP地址。

操作步骤

步骤1 开启对DHCP报文进行绑定表匹配检查的功能

在VLAN视图下执行以下命令，对属于该VLAN的所有接口都生效；在接口下执行该命令，仅对该接口生效。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**vlan vlan-id**，进入VLAN视图；或执行命令**interface interface-type interface-number**，进入接口视图。
3. 执行命令**dhcp snooping check dhcp-request enable**，开启对DHCP报文进行绑定表匹配检查的功能。

缺省情况下，未开启对DHCP报文进行绑定表匹配检查的功能。

4. 执行命令**dhcp snooping check mac-address enable**，开启检测DHCP Request报文帧头源MAC地址与CHADDR字段是否相同的功能。

缺省情况下，未开启检测DHCP Request报文帧头源MAC地址与CHADDR字段是否相同的功能。

步骤2 （可选）开启DHCP Snooping告警功能

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**interface interface-type interface-number**，进入接口视图。
3. 执行命令**dhcp snooping alarm { user-bind | mac-address | untrust-reply | dhcpv6-request } enable**，开启DHCP Snooping告警功能。

缺省情况下，未开启DHCP Snooping告警功能。

步骤3 （可选）配置告警阈值

若在系统视图、接口视图下同时进行了配置，则接口下DHCP Snooping丢弃报文数量的告警阈值以两者最小值为准。

- 系统视图下：

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**dhcp snooping alarm threshold threshold**，配置DHCP Snooping丢弃报文数量的告警阈值。

在系统视图下执行该命令，则对设备所有的接口该命令功能生效。

缺省情况下，DHCP Snooping丢弃报文数量的告警阈值为100packets。

- 接口视图下：

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**interface interface-type interface-number**，进入接口视图。
3. 执行命令**dhcp snooping alarm { user-bind | mac-address | untrust-reply | dhcpv6-request } threshold threshold**，配置DHCP Snooping丢弃报文数量的告警阈值。

缺省情况下，全局DHCP Snooping丢弃报文数量的告警阈值为100packets，接口下DHCP Snooping丢弃报文数量的告警阈值为在系统视图下使用命令**dhcp snooping alarm threshold**配置的值。

----结束

13.7.3 配置防止 DHCP Server 服务拒绝攻击

背景信息

若在网络中存在DHCP用户恶意申请IP地址，将会导致IP地址池中的IP地址快速耗尽以致DHCP Server无法为其他合法用户分配IP地址。另一方面，DHCP Server通常仅根据CHADDR（client hardware address）字段来确认客户端的MAC地址。如果攻击者通过不断改变DHCP Request报文中的CHADDR字段向DHCP Server申请IP地址，将会导致DHCP Server上的地址池被耗尽，从而无法为其他正常用户提供IP地址。

为了防止某些端口的DHCP用户恶意申请IP地址，可配置接口允许学习的DHCP Snooping绑定表项的最大个数，当用户数达到该值时，则任何用户将无法通过此接口成功申请到IP地址。为了防止攻击者不断改变DHCP Request报文中的CHADDR字段进

行攻击，可使能检测DHCP Request报文帧头MAC地址与DHCP数据区中CHADDR字段是否相同的功能，相同则转发报文，否则丢弃。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置接口允许学习的DHCP Snooping绑定表项的最大个数，可在VLAN视图或接口视图下配置。

1. 执行命令**vlan *vlan-id***，进入VLAN视图；或执行命令**interface *interface-type* *interface-number***，进入接口视图。
2. 执行命令**dhcp snooping max-user-number *max-user-number***，配置接口允许学习的DHCP Snooping绑定表项的最大个数。

若在VLAN视图下执行该命令，则VLAN内所有的接口接入的用户最大数为该命令所配置的值。

步骤3 使能对报文的CHADDR字段进行检查功能，可在VLAN视图或接口视图下进行配置。

1. 执行命令**vlan *vlan-id***，进入VLAN视图；或执行命令**interface *interface-type* *interface-number***，进入接口视图。
2. 执行命令**dhcp snooping check mac-address enable**，使能检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能。

缺省情况下，未使能检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能。

在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCP报文命令功能生效；在接口下执行该命令，则仅对该接口接收到的所有DHCP报文命令功能生效。

3. 执行命令**quit**，返回到系统视图。

步骤4 （可选）配置DHCP Snooping丢弃报文数量的告警阈值，可在系统视图或接口视图下执行。

- 系统视图下：

1. 执行命令**dhcp snooping alarm threshold *threshold***，配置全局DHCP Snooping丢弃报文数量的告警阈值。

在系统视图下执行该命令，则设备所有的接口该命令功能生效。

缺省情况下，全局DHCP Snooping丢弃报文数量的告警阈值为100packets。

- 接口视图下：

1. 执行命令**interface *interface-type* *interface-number***，进入接口视图。
2. 执行命令**dhcp snooping alarm mac-address threshold *threshold***，配置帧头MAC地址与DHCP数据区中CHADDR字段不匹配而被丢弃的DHCP报文的告警阈值。

缺省情况下，全局DHCP Snooping丢弃报文数量的告警阈值为100packets，接口下DHCP Snooping丢弃报文数量的告警阈值为在系统视图下使用命令**dhcp snooping alarm threshold**配置的值。

说明

若在系统视图、接口视图下同时进行了配置，则接口下DHCP Snooping丢弃报文数量的告警阈值以两者最小值为准。

----结束

13.7.4 检查 DHCP Snooping 攻击防范功能的配置结果

背景信息

DHCP Snooping的攻击防范功能配置完成后，可使用命令查看已配置的参数信息。

操作步骤

- 执行命令**display dhcp snooping [interface interface-type interface-number | vlan vlan-id]**，查看DHCP Snooping的运行信息。
- 执行命令**display dhcp snooping configuration [vlan vlan-id | interface interface-type interface-number]**，查看DHCP Snooping的配置信息。
- 执行命令**display dhcp snooping statistics { global | vlan vlan-id | interface interface-type interface-number }**，查看设备接收到的各类型DHCP报文的统计信息。

----结束

13.8 配置在 DHCP 报文中添加 Option82 字段

背景信息

Option82选项记录了DHCP Client的位置信息。设备通过在DHCP请求报文中添加Option82选项，可将DHCP Client的位置信息发送给DHCP Server，从而使得DHCP Server能够根据Option82选项的内容为DHCP Client分配合适的IP地址和其他配置信息，并可以实现对客户端的安全控制。

说明

- DHCP Option82必须配置在设备的用户侧，否则设备向DHCP Server发出的DHCP报文不会携带Option82选项内容。
- 所有Option82选项共用1~255个字节长度，因此，所有Option82选项长度之和不能超过255个字节，否则会导致部分Option82选项信息丢失。
- 设备不限制配置多少个Option82选项，但是大量配置会占用很多内存，并延长设备处理时间。为保证设备性能，建议用户根据自身需要和设备内存大小来配置Option82选项。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 使能在DHCP报文中添加Option82选项功能，可在VLAN视图或接口视图下进行配置。

视图	操作步骤
VLAN视图	1. 执行命令 vlan <i>vlan-id</i> ，进入VLAN视图。 2. 执行命令 dhcp option82 { insert rebuild } enable ，使能在DHCP报文中添加Option82选项功能。 缺省情况下，未使能在DHCP报文中添加Option82选项功能。 3. 执行命令 quit ，返回到系统视图。
接口视图	1. 执行命令 interface <i>interface-type interface-number</i> ，进入接口视图。 2. 执行命令 dhcp option82 { insert rebuild } enable ，使能在DHCP报文中添加Option82选项功能。 缺省情况下，未使能在DHCP报文中添加Option82选项功能。 3. 执行命令 quit ，返回到系统视图。

步骤3 （可选）配置Option82选项的格式，可在系统视图或接口视图下进行配置。在系统视图下进行配置，对设备所有的接口功能生效；在接口下进行配置，仅对指定的接口功能生效。

视图	操作步骤
系统视图	1. 执行命令 dhcp option82 [vlan <i>vlan-id</i>] [ce-vlan <i>ce-vlan-id</i>] [circuit-id remote-id] format { default common extend user-defined <i>text</i> } ，配置在DHCP报文中添加的Option82选项的格式。 缺省情况下，在DHCP报文中添加的Option82选项的格式为 default 格式。
接口视图	1. 执行命令 interface <i>interface-type interface-number</i> ，进入接口视图。 2. 执行命令 dhcp option82 [vlan <i>vlan-id</i>] [ce-vlan <i>ce-vlan-id</i>] [circuit-id remote-id] format { default common extend user-defined <i>text</i> } ，配置在DHCP报文中添加的Option82选项的格式。 缺省情况下，在DHCP报文中添加的Option82选项的格式为 default 格式。 3. 执行命令 quit ，返回到系统视图。

步骤4 （可选）执行命令**dhcp option82 subscriber-id format { ascii *ascii-text* | hex *hex-text* }**，配置在DHCP报文的Option82选项中插入Sub6子选项。

缺省情况下，未配置在DHCP报文的Option82选项中插入Sub6子选项。

步骤5 （可选）配置在DHCP报文的Option82选项中插入Sub9子选项。

Option82选项的Sub9子选项分为新旧两种格式，旧格式携带hwid或其他公司的ID，新格式不携带。

- 执行命令**dhcp option82 vendor-specific format vendor-sub-option sub-option-num { ascii *ascii-text* | hex *hex-text* | ip-address *ip-address* &<1-8> | sysname }**，配置在DHCP报文的Option82选项中插入旧格式的Sub9子选项。
- 配置在DHCP报文的Option82选项中插入新格式的Sub9子选项。

视图	操作步骤
VLAN视图	1. 执行命令 vlan <i>vlan-id</i> ，进入VLAN视图。 2. 执行命令 dhcp option82 append vendor-specific ，配置在DHCP报文的Option82选项中插入新格式的Sub9子选项。 3. 执行命令 quit ，返回到系统视图。
接口视图	1. 执行命令 interface <i>interface-type interface-number</i> ，进入接口视图。 2. 执行命令 dhcp option82 append vendor-specific ，配置在DHCP报文的Option82选项中插入新格式的Sub9子选项。 3. 执行命令 quit ，返回到系统视图。

缺省情况下，未配置在DHCP报文的Option82选项中插入Sub9子选项。

 说明

- 命令**dhcp option82 append vendor-specific**和命令**dhcp option82 vendor-specific format**同时配置时，前者生效。
- 只有设备上配置的Sub9子选项格式与接收到的DHCP报文中的格式一致时，Sub9子选项才能插入到Option82选项中。如果格式不一致：
 - 当配置命令**dhcp option82 vendor-specific format**时，新格式的Sub9子选项不能插入到Option82选项中。
 - 当配置命令**dhcp option82 append vendor-specific**时，旧格式的Sub9子选项信息能否插入到Option82选项中，还取决于Option82选项的添加方式（通过命令**dhcp option82 enable**配置）：
 - Insert方式时，不会被插入到Option82选项。
 - Rebuild方式时，旧格式的Sub9子选项信息被重构，然后被插入到Option82选项。

步骤6 （可选）配置插入DHCP Option82选项中的子选项，可在系统视图、VLAN视图或接口视图下进行配置。在系统视图下进行配置，对设备所有的接口功能生效；在VLAN视图下进行配置，对设备所有接口接收到的属于该VLAN的DHCP报文功能生效；在接口下进行配置，仅对指定的接口功能生效。

视图	操作步骤
系统视图	1. 执行命令 dhcp option82 encapsulation { circuit-id remote-id subscriber-id vendor-specific-id } * ，配置插入DHCP Option82选项中的子选项。 缺省情况下，插入DHCP Option82选项中的子选项为circuit-id（CID）子选项和remote-id（RID）子选项。

视图	操作步骤
VLAN视图	1. 执行命令 vlan <i>vlan-id</i> ，进入VLAN视图。 2. 执行命令 dhcp option82 encapsulation { circuit-id remote-id subscriber-id vendor-specific-id } * ，配置插入DHCP Option82选项中的子选项。 缺省情况下，插入DHCP Option82选项中的子选项为circuit-id（CID）子选项和remote-id（RID）子选项。 3. 执行命令 quit ，返回到系统视图。
接口视图	1. 执行命令 interface <i>interface-type interface-number</i> ，进入接口视图。 2. 执行命令 dhcp option82 encapsulation { circuit-id remote-id subscriber-id vendor-specific-id } * ，配置插入DHCP Option82选项中的子选项。 缺省情况下，插入DHCP Option82选项中的子选项为circuit-id（CID）子选项和remote-id（RID）子选项。 3. 执行命令 quit ，返回到系统视图。

步骤7 （可选）配置在使能DHCP Snooping功能后，接口不生成用户绑定表。

基于VLAN进行配置，表示对设备所有接口下连接的属于该VLAN的DHCP用户，命令功能生效；基于接口进行配置，表示对设备该接口下连接的所有DHCP用户，命令功能生效。

缺省情况下，在使能DHCP Snooping功能后，接口生成用户绑定表。

配置维度	操作步骤
基于VLAN配置	在系统视图下针对多个VLAN批量配置 - 执行命令dhcp snooping enable no-user-binding vlan { <i>vlan-id1</i> [to <i>vlan-id2</i>] } <1-10>，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 在VLAN视图下针对单个VLAN配置 - 执行命令vlan <i>vlan-id</i>，进入VLAN视图。 - 执行命令dhcp snooping enable no-user-binding，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 - 执行命令quit，返回到系统视图。
基于接口配置	- 执行命令interface <i>interface-type interface-number</i>，进入接口视图。 - 执行命令dhcp snooping enable no-user-binding，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 - 执行命令quit，返回到系统视图。

----结束

检查配置结果

- 执行命令**display dhcp option82 configuration [vlan *vlan-id* | interface *interface-type interface-number*]**，查看DHCP Option82的配置信息。

13.9 配置通过 LDRA 功能感知用户位置

背景信息

在DHCPv6网络中，为获取用户详细的位置信息，可在靠近用户的接入设备上部署LDRA功能。

在使能LDRA功能之后，如果管理员信任DHCPv6网络中的用户，并且用户较多时，可取消DHCP Snooping记录用户绑定表项功能，否则一旦设备上的绑定表项数目达到最大值，新用户将无法上线。另一方面，设备通过在Relay-Forward报文中插入interface-id与remote-id选项以记录用户的位置信息，管理员可根据用户实际位置情况配置interface-id与remote-id选项的格式。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**vlan *vlan-id***，进入VLAN视图。

步骤3 执行命令**dhcpv6 snooping relay-information enable [trust]**，使能DHCPv6 Snooping支持的LDRA功能。

缺省情况下，未使能DHCPv6 Snooping支持的LDRA功能。

步骤4 执行命令**quit**，返回到系统视图。

步骤5 （可选）执行命令**dhcpv6 interface-id format { default | user-defined *text* }**，配置在DHCPv6报文中添加的interface-id的格式。

缺省情况下，DHCPv6报文中添加的interface-id的格式为**default**。

步骤6 （可选）执行命令**dhcpv6 remote-id format { default | user-defined *text* }**，配置在DHCPv6报文中添加的remote-id的格式。

缺省情况下，DHCPv6报文中添加的remote-id的格式为**default**。

步骤7 （可选）配置在使能DHCP Snooping功能后，接口不生成用户绑定表。

基于VLAN进行配置，表示对设备所有接口下连接的属于该VLAN的DHCP用户，命令功能生效；基于接口进行配置，表示对设备该接口下连接的所有DHCP用户，命令功能生效。

缺省情况下，在使能DHCP Snooping功能后，接口生成用户绑定表。

配置维度	操作步骤
基于VLAN配置	在系统视图下针对多个VLAN批量配置 - 执行命令dhcp snooping enable no-user-binding vlan { vlan-id1 [to vlan-id2] }&<1-10>，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 在VLAN视图下针对单个VLAN配置 - 执行命令vlan vlan-id，进入VLAN视图。 - 执行命令dhcp snooping enable no-user-binding，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 - 执行命令quit，返回到系统视图。
基于接口配置	- 执行命令interface interface-type interface-number，进入接口视图。 - 执行命令dhcp snooping enable no-user-binding，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 - 执行命令quit，返回到系统视图。

----结束

13.10 配置在 DHCPv6 报文中添加 Option18 或 Option37 字段

背景信息

DHCPv6报文中的Option18与Option37选项功能与DHCPv4报文中的Option82选项功能类似，其中Option18选项记录了客户端的接口信息，Option37选项记录了客户端的MAC地址信息。设备通过在DHCPv6请求报文中添加Option18或Option37选项，可将DHCPv6 Client的位置信息发送给DHCP Server，从而使得DHCP Server能够根据Option18或Option37选项的内容为DHCPv6 Client分配合适的IP地址和其他配置信息，并实现对客户端的安全控制。

操作步骤

- 步骤1 执行命令**system-view**，进入系统视图。
- 步骤2 执行命令**interface interface-type interface-number**，进入接口视图。
- 步骤3 执行命令**dhcpv6 { option18 | option37 } { insert | rebuild } enable**，使能在DHCPv6 Request报文中添加Option18或Option37选项的功能。

缺省情况下，未使能在DHCPv6报文中添加Option18或Option37选项的功能。

说明

在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCPv6报文命令功能生效；在接口下执行该命令，则仅对该接口接收到的所有DHCPv6报文命令功能生效。

- 步骤4 执行命令**quit**，返回到系统视图。

步骤5 （可选）配置在DHCPv6报文中添加的Option18选项的格式，可在系统视图、VLAN视图或接口视图下执行。

- 系统视图下：
 - a. 执行命令（可选）执行命令**dhcpv6 option18 [vlan *vlan-id*] [ce-vlan *ce-vlan-id*] format user-defined *text***，配置在DHCPv6报文中添加的Option18选项的格式。
缺省情况下，未配置在DHCPv6报文中添加的Option18选项的格式。
- VLAN视图下：
 - a. 执行命令**vlan *vlan-id***，进入VLAN视图。
 - b. （可选）执行命令**dhcpv6 option18 format user-defined *text***，配置在DHCPv6报文中添加的Option18选项的格式。
缺省情况下，未配置在DHCPv6报文中添加的Option18选项的格式。
- 接口视图下：
 - a. 执行命令**interface *interface-type interface-number***，进入接口视图。
 - b. （可选）执行命令**dhcpv6 option18 [vlan *vlan-id*] [ce-vlan *ce-vlan-id*] format user-defined *text***，配置在DHCPv6报文中添加的Option18选项的格式。
缺省情况下，未配置在DHCPv6报文中添加的Option18选项的格式。

说明

在系统视图下执行此命令，则对所有DHCPv6报文的Option18选项生效；在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCPv6报文的Option18选项生效；在接口下执行该命令，则仅对该接口接收到的所有DHCPv6报文的Option18选项生效。

步骤6 （可选）配置在DHCPv6报文中添加的Option37选项的格式，可在系统视图、VLAN视图或接口视图下执行。

- 系统视图下：
 - a. 执行命令**dhcpv6 option37 [vlan *vlan-id*] [ce-vlan *ce-vlan-id*] format user-defined *text***，配置在DHCPv6报文中添加的Option37选项的格式。
缺省情况下，未配置在DHCPv6报文中添加的Option37选项的格式。
- VLAN视图下：
 - a. 执行命令**vlan *vlan-id***，进入VLAN视图。
 - b. 执行命令**dhcpv6 option37 format user-defined *text***，配置在DHCPv6报文中添加的Option37选项的格式。
缺省情况下，未配置在DHCPv6报文中添加的Option37选项的格式。
- 接口视图下：
 - a. 执行命令**interface *interface-type interface-number***，进入接口视图。
 - b. 执行命令**dhcpv6 option37 [vlan *vlan-id*] [ce-vlan *ce-vlan-id*] format user-defined *text***，配置在DHCPv6报文中添加的Option37选项的格式。
缺省情况下，未配置在DHCPv6报文中添加的Option37选项的格式。

说明

在系统视图下执行此命令，则对所有DHCPv6报文的Option37选项生效；在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCPv6报文的Option37选项生效；在接口下执行该命令，则仅对该接口接收到的所有DHCPv6报文的Option37选项生效。

----结束

13.11 维护 DHCP Snooping

13.11.1 清除 DHCP Snooping 的统计信息

背景信息

须知

清除统计信息后，以前的统计信息将无法恢复，请慎重操作。

操作步骤

- 在用户视图下执行命令**reset dhcp snooping statistics global**，清除全局的报文丢弃统计计数。
- 在用户视图下执行命令**reset dhcp snooping statistics interface *interface-type* *interface-number* [*vlan* *vlan-id*]**，清除接口下的报文丢弃统计计数。
- 在用户视图下执行命令**reset dhcp snooping statistics vlan *vlan-id* [interface *interface-type* *interface-number*]**，清除VLAN下的报文丢弃统计计数。

----结束

13.11.2 清除 DHCP Snooping 绑定表

背景信息

由于在组网环境变化之后，DHCP Snooping绑定表不会立即老化，而DHCP Snooping绑定表匹配的如下信息可能会发生变化，导致报文转发错误。

- 用户所属VLAN信息。
- 用户所连接的接口信息。

所以，请在变更组网环境之前手动清除所有DHCP Snooping绑定表项，使得设备根据新的网络环境生成新的DHCP Snooping绑定表。

须知

清除DHCP Snooping绑定表后，设备下所连接的所有DHCP用户均需重新上线生成绑定表后方可恢复正常网络通信，请慎重操作。

操作步骤

- 在用户视图下执行命令`reset dhcp snooping user-bind [ [ vlan vlan-id | interface interface-type interface-number ] * | ip-address [ ip-address ] | ipv6-address [ ipv6-address ] ]`，清除DHCP Snooping绑定表。

----结束

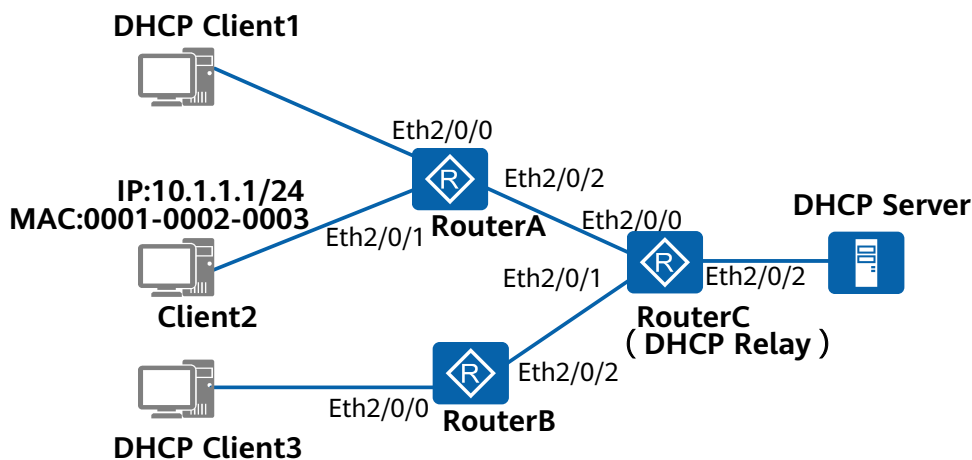
13.12 DHCP Snooping 配置举例

13.12.1 配置 DHCP Snooping 的攻击防范功能示例

组网需求

如图13-8所示，RouterA与RouterB为接入设备，RouterC为DHCP Relay。Client1与Client2分别通过Eth2/0/0与Eth2/0/1接入RouterA，Client3通过Eth2/0/0接入RouterB，其中Client1与Client3通过DHCP方式获取IP地址，而Client2使用静态配置的IP地址。网络中存在非法用户的攻击导致合法用户不能正常获取IP地址，管理员希望能够防止网络中针对DHCP的攻击，为DHCP用户提供更优质的服务。

图 13-8 配置 DHCP Snooping 的攻击防范功能组网图



配置思路

采用如下的思路在RouterC上进行配置。

1. 使能DHCP Snooping功能。
2. 配置接口的信任状态，以保证客户端从合法的服务器获取IP地址。
3. 使能ARP与DHCP Snooping的联动功能，保证DHCP用户在异常下线时实时更新绑定表。
4. 使能对DHCP报文进行绑定表匹配检查的功能，防止仿冒DHCP报文攻击。

5. 配置允许接入的最大用户数以及使能检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能，防止DHCP Server服务拒绝攻击。
6. 配置丢弃报文告警和报文限速告警功能。

操作步骤

步骤1 使能DHCP Snooping功能。

使能全局DHCP Snooping功能。

```
<Huawei> system-view
[Huawei] sysname RouterC
[RouterC] dhcp enable
[RouterC] dhcp snooping enable
```

使能用户侧接口的DHCP Snooping功能。以Eth2/0/0接口为例，Eth2/0/1的配置与Eth2/0/0接口相同，不再赘述。

```
[RouterC] interface ethernet 2/0/0
[RouterC-Ethernet2/0/0] dhcp snooping enable
[RouterC-Ethernet2/0/0] quit
```

步骤2 配置接口的信任状态：将连接DHCP Server的接口状态配置为“Trusted”。

```
[RouterC] interface ethernet 2/0/2
[RouterC-Ethernet2/0/2] dhcp snooping trusted
[RouterC-Ethernet2/0/2] quit
```

步骤3 使能ARP与DHCP Snooping的联动功能。

```
[RouterC] arp dhcp-snooping-detect enable
```

步骤4 使能对DHCP报文进行绑定表匹配检查的功能。

在用户侧接口进行配置。以Eth2/0/0接口为例，Eth2/0/1的配置与Eth2/0/0接口相同，不再赘述。

```
[RouterC] interface ethernet 2/0/0
[RouterC-Ethernet2/0/0] dhcp snooping check user-bind enable
[RouterC-Ethernet2/0/0] quit
```

步骤5 使能检测DHCP Request报文中GIADDR字段是否非零的功能。

在用户侧接口进行配置。以Eth2/0/0接口为例，Eth2/0/1的配置与Eth2/0/0接口相同，不再赘述。

```
[RouterC] interface ethernet 2/0/0
[RouterC-Ethernet2/0/0] dhcp snooping check dhcp-giaddr enable
[RouterC-Ethernet2/0/0] quit
```

步骤6 配置接口允许接入的最大用户数并使能对CHADDR字段检查功能。

在用户侧接口进行配置。以Eth2/0/0接口为例，Eth2/0/1的配置与Eth2/0/0接口相同，不再赘述。

```
[RouterC] interface ethernet 2/0/0
[RouterC-Ethernet2/0/0] dhcp snooping max-user-number 20
[RouterC-Ethernet2/0/0] dhcp snooping check mac-address enable
[RouterC-Ethernet2/0/0] quit
```

步骤7 配置丢弃报文告警和报文限速告警功能。

使能丢弃报文告警功能，并配置丢弃报文告警阈值。以Eth2/0/0接口为例，Eth2/0/1的配置与Eth2/0/0接口相同，不再赘述。

```
[RouterC] interface ethernet 2/0/0
[RouterC-Ethernet2/0/0] dhcp snooping alarm mac-address enable
```

```
[RouterC-Ethernet2/0/0] dhcp snooping alarm user-bind enable
[RouterC-Ethernet2/0/0] dhcp snooping alarm untrust-reply enable
[RouterC-Ethernet2/0/0] dhcp snooping alarm mac-address threshold 120
[RouterC-Ethernet2/0/0] dhcp snooping alarm user-bind threshold 120
[RouterC-Ethernet2/0/0] dhcp snooping alarm untrust-reply threshold 120
[RouterC-Ethernet2/0/0] quit
```

步骤8 验证配置结果。

执行命令**display dhcp snooping configuration**查看DHCP Snooping的配置信息。

```
[RouterC] display dhcp snooping configuration
#
dhcp snooping enable
arp dhcp-snooping-detect enable
#
interface Ethernet2/0/0
  dhcp snooping enable
  dhcp snooping check dhcp-giaddr enable
  dhcp snooping check user-bind enable
  dhcp snooping alarm user-bind enable
  dhcp snooping alarm user-bind threshold 120
  dhcp snooping check mac-address enable
  dhcp snooping alarm mac-address enable
  dhcp snooping alarm mac-address threshold 120
  dhcp snooping alarm untrust-reply enable
  dhcp snooping alarm untrust-reply threshold 120
  dhcp snooping max-user-number 20
#
interface Ethernet2/0/1
  dhcp snooping enable
  dhcp snooping check dhcp-giaddr enable
  dhcp snooping check user-bind enable
  dhcp snooping alarm user-bind enable
  dhcp snooping alarm user-bind threshold 120
  dhcp snooping check mac-address enable
  dhcp snooping alarm mac-address enable
  dhcp snooping alarm mac-address threshold 120
  dhcp snooping alarm untrust-reply enable
  dhcp snooping alarm untrust-reply threshold 120
  dhcp snooping max-user-number 20
#
interface Ethernet2/0/2
  dhcp snooping trusted
#
```

执行命令**display dhcp snooping interface**查看接口下的DHCP Snooping运行信息。

```
[RouterC] display dhcp snooping interface ethernet 2/0/0
DHCP snooping running information for interface Ethernet2/0/0 :
DHCP snooping                : Enable
Trusted interface             : No
Dhcp user max number          : 20
Current dhcp user number      : 0
Check dhcp-giaddr             : Enable
Check dhcp-chaddr             : Enable
Alarm dhcp-chaddr             : Enable
Alarm dhcp-chaddr threshold   : 120
Discarded dhcp packets for check chaddr : 0
Check dhcp-request            : Enable
Alarm dhcp-request            : Enable
Alarm dhcp-request threshold   : 120
Discarded dhcp packets for check request : 0
Alarm dhcp-reply              : Enable
Alarm dhcp-reply threshold     : 120
Discarded dhcp packets for check reply : 0
[RouterC] display dhcp snooping interface ethernet 2/0/2
DHCP snooping running information for interface Ethernet2/0/2 :
DHCP snooping                : Disable (default)
```

```
Trusted interface          : Yes
Dhcp user max number       : 512  (default)
Current dhcp user number   : 0
Check dhcp-giaddr          : Disable (default)
Check dhcp-chaddr          : Disable (default)
Alarm dhcp-chaddr          : Disable (default)
Check dhcp-request         : Disable (default)
Alarm dhcp-request         : Disable (default)
Alarm dhcp-reply           : Disable (default)
```

----结束

配置文件

RouterC的配置文件

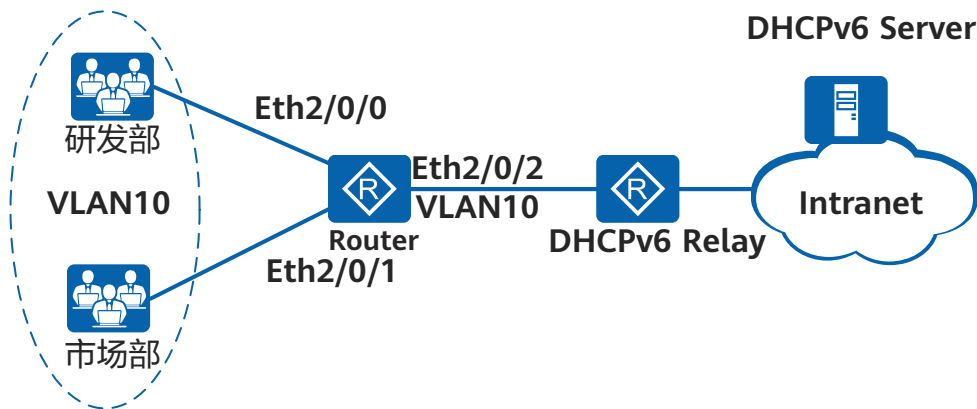
```
#
sysname RouterC
#
dhcp enable
#
dhcp snooping enable
arp dhcp-snooping-detect enable
#
interface Ethernet2/0/0
 dhcp snooping enable
 dhcp snooping check dhcp-giaddr enable
 dhcp snooping check user-bind enable
 dhcp snooping alarm user-bind enable
 dhcp snooping alarm user-bind threshold 120
 dhcp snooping check mac-address enable
 dhcp snooping alarm mac-address enable
 dhcp snooping alarm mac-address threshold 120
 dhcp snooping alarm untrust-reply enable
 dhcp snooping alarm untrust-reply threshold 120
 dhcp snooping max-user-number 20
#
interface Ethernet2/0/1
 dhcp snooping enable
 dhcp snooping check dhcp-giaddr enable
 dhcp snooping check user-bind enable
 dhcp snooping alarm user-bind enable
 dhcp snooping alarm user-bind threshold 120
 dhcp snooping check mac-address enable
 dhcp snooping alarm mac-address enable
 dhcp snooping alarm mac-address threshold 120
 dhcp snooping alarm untrust-reply enable
 dhcp snooping alarm untrust-reply threshold 120
 dhcp snooping max-user-number 20
#
interface Ethernet2/0/2
 dhcp snooping trusted
#
return
```

13.12.2 配置通过 LDRA 功能感知用户位置示例

组网需求

如图13-9所示，某公司研发部与市场部通过Router接入网络并通过DHCPv6方式获取IPv6地址。由于研发部与市场部工作性质不同，所以该公司希望DHCPv6服务器能够判別出研发与市场部不同的客户端，进而为这两个部门部署不同的地址分配、接入控制、QOS等策略。

图 13-9 配置 LDRA 功能组网图



配置思路

采用如下的思路在Router上进行配置。

1. 使能DHCP Snooping功能，为使能LDRA功能做准备。
2. 使能LDRA功能。通过在靠近用户的接入设备Router上部署LDRA功能，能够将用户详细的位置信息上送至DHCPv6 Server，满足DHCPv6 Server根据用户详细位置信息为用户部署各种策略的需求。

操作步骤

步骤1 创建VLAN并配置各接口

在Router上创建VLAN10。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10
```

将接口Eth2/0/0、Eth2/0/1、Eth2/0/2加入到VLAN10中。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type access
[Router-Ethernet2/0/0] port default vlan 10
[Router-Ethernet2/0/0] quit
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] port link-type access
[Router-Ethernet2/0/1] port default vlan 10
[Router-Ethernet2/0/1] quit
[Router] interface ethernet 2/0/2
[Router-Ethernet2/0/2] port link-type trunk
[Router-Ethernet2/0/2] port trunk allow-pass vlan 10
[Router-Ethernet2/0/2] quit
```

步骤2 使能DHCP Snooping功能

使能全局DHCP Snooping功能。

```
[Router] dhcp enable
[Router] dhcp snooping enable
```

使能用户侧接口的DHCP Snooping功能。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] dhcp snooping enable
```

```
[Router-Ethernet2/0/0] quit
[Router] interface ethernet 2/0/1
[Router-Ethernet2/0/1] dhcp snooping enable
[Router-Ethernet2/0/1] quit
```

配置接口的信任状态，将连接DHCPv6 Server的接口状态配置为“Trusted”。

```
[Router] interface ethernet 2/0/2
[Router-Ethernet2/0/2] dhcp snooping trusted
[Router-Ethernet2/0/2] quit
```

步骤3 使能LDRA功能

在VLAN10下使能LDRA功能。

```
[Router] vlan 10
[Router-vlan10] dhcpv6 snooping relay-information enable
```

在VLAN10下配置在使能DHCP Snooping功能后，接口不生成用户绑定表，以使设备不会对上线用户数目进行限制。

```
[Router-vlan10] dhcp snooping enable no-user-binding
Warning: To execute no-user-binding will delete all dynamic binding table with the same vlan. Continue?
[Y/N]y
[Router-vlan10] quit
```

步骤4 验证配置结果

执行命令**display dhcp snooping configuration**查看LDRA的相关配置信息。

```
[Router] display dhcp snooping configuration
#
dhcp snooping enable
#
vlan 10
  dhcp snooping enable no-user-binding
  dhcpv6 snooping relay-information enable
#
interface Ethernet2/0/0
  dhcp snooping enable
#
interface Ethernet2/0/1
  dhcp snooping enable
#
interface Ethernet2/0/2
  dhcp snooping trusted
#
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10
#
dhcp enable
#
dhcp snooping enable
#
vlan 10
  dhcp snooping enable no-user-binding
  dhcpv6 snooping relay-information enable
#
interface Ethernet2/0/0
```

```
port link-type access
port default vlan 10
dhcp snooping enable
#
interface Ethernet2/0/1
port link-type access
port default vlan 10
dhcp snooping enable
#
interface Ethernet2/0/2
port link-type trunk
port trunk allow-pass vlan 10
dhcp snooping trusted
#
return
```

13.13 DHCP Snooping 常见配置错误

13.13.1 DHCP Snooping 导致用户无法上线

故障现象

DHCP Snooping导致用户无法上线可能由以下原因造成：

- 连接DHCP Server的网络侧接口未配置为“信任”状态
- 用户侧接口下DHCP用户数达到配置的最大值

操作步骤

步骤1 查看接口状态是否配置错误。

1. 执行命令**display dhcp snooping configuration**查看在哪些VLAN下、哪些接口下使能了DHCP Snooping功能并查看网络侧接口下是否有“Trusted interface”信息。

说明

- “Trusted”是接口信任状态的标识。接口使能了DHCP Snooping功能后，默认为“非信任”状态。对网络侧报文：设备只处理信任接口收到的DHCP Reply报文，非信任接口收到DHCP Reply报文会丢弃；对用户侧报文：设备收到用户的请求报文时，只会向信任接口转发。
2. 连接DHCP Server的网络侧接口应该配置为“Trusted”。如果网络侧接口不是信任接口，可在VLAN视图或接口视图下执行命令**dhcp snooping trusted**，配置接口为信任状态。

步骤2 如果接口信任状态配置正确，则查看DHCP上线用户数是否达到配置的最大值。

1. 执行命令**display dhcp snooping configuration**，查看全局、VLAN、以及用户侧接口下是否有“DHCP user max number: XX”信息。

说明

若没有“DHCP user max number: XX”信息，则接口允许接入的最大DHCP用户数取默认值512个。若配置了该信息则以配置值为准。

如果在系统视图、VLAN视图、接口视图下均配置了该参数，则接口下允许接入的最大DHCP用户为三者中的最小值。

2. 执行命令**display dhcp snooping user-bind all**，查看当前设备使能DHCP Snooping功能的接口上一共生成多少DHCP用户动态绑定表项。如果表项数已经达到配置的限制值，后续用户无法接入不属于故障。

----结束

13.14 DHCP Snooping FAQ

13.14.1 设备上如果没有 LAN 板，可以实现 DHCP Snooping 功能吗？

DHCP Snooping功能只能在LAN板上实现。

如果想对源MAC地址做相应限制，可以使用二层ACL，但这不是DHCP Snooping的替代功能。

14 IPSP 配置

配置IPSP功能，对接收到的IP报文进行绑定表匹配检查，可以有效的防止基于源地址欺骗的网络攻击行为。

14.1 IPSP简介

介绍IPSP的定义、背景和作用。

14.2 IPSP原理描述

介绍IPSP的实现原理、应用在网络中的位置以及和其他相关特性（DAI、静态ARP、端口安全）的比较。

14.3 IPSP应用场景

介绍IPSP在园区网中的常见应用，如通过IPSP防止主机私自更改IP地址上网、限制非法主机接入网络。

14.4 IPSP配置注意事项

介绍配置IPSP的注意事项。

14.5 IPSP缺省配置

介绍IPSP的缺省配置，实际应用的配置可以基于缺省配置进行修改。

14.6 配置IPSP

分别介绍基于静态绑定表和动态绑定表两种方式下的IPSP的配置过程。

14.7 IPSP配置举例

通过示例介绍IPSP如何防止主机私自更改IP地址、避免非法主机访问内网，提供组网图、配置步骤和配置文件等。

14.8 IPSP常见配置错误

介绍IPSP常见的配置错误导致的故障问题（如接口未使能导致IPSP业务不生效），并给出正确的配置。

14.9 IPSP FAQ

提供IPSP的常见问题集。例如：IPSP是否支持批量绑定、IPSP不生效有哪些原因等。

14.1 IPSP 简介

介绍IPSP的定义、背景和作用。

定义

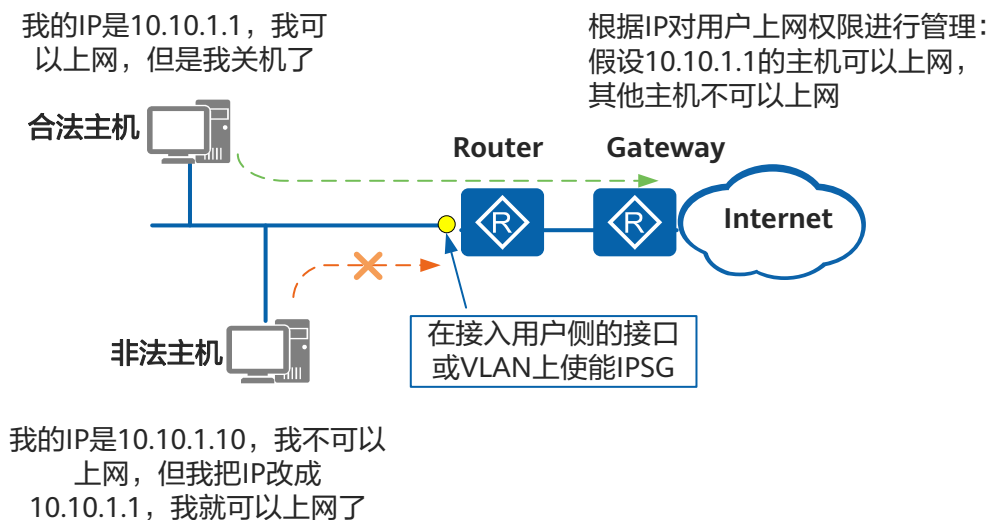
IP源防攻击IPSG（IP Source Guard）是一种基于二层接口的源IP地址过滤技术，它能够防止恶意主机伪造合法主机的IP地址来仿冒合法主机，还能确保非授权主机不能通过自己指定IP地址的方式来访问网络或攻击网络。

目的

随着网络规模越来越大，通过伪造源IP地址实施的网络安全攻击（简称IP地址欺骗攻击）也逐渐增多。一些攻击者通过伪造合法用户的IP地址获取网络访问权限，非法访问网络，甚至造成合法用户无法访问网络，或者信息泄露。IPSG针对IP地址欺骗攻击提供了一种防御机制，可以有效阻止此类网络安全行为。

一个典型的利用IPSG防攻击的示例如图14-1所示，非法主机伪造合法主机的IP地址获取上网权限。此时，通过在设备的接入用户侧的接口或VLAN上部署IPSG功能，设备可以对进入接口的IP报文进行检查，丢弃非法主机的报文，从而阻止此类攻击。

图 14-1 IPSG 典型防攻击示例图



14.2 IPSG 原理描述

介绍IPSG的实现原理、应用在网络中的位置以及和其他相关特性（DAI、静态ARP、端口安全）的比较。

14.2.1 基本原理

IPSG利用绑定表（源IP地址、源MAC地址、所属VLAN、入接口的绑定关系）去匹配检查二层接口上收到的IP报文，只有匹配绑定表的报文才允许通过，其他报文将被丢弃。

绑定表如表14-1所示，包括静态和动态两种。

表 14-1 绑定表

绑定表类型	生成过程	适用场景
静态绑定表	使用user-bind命令手工配置。	适用于主机数较少且主机使用静态IP地址的场景。
DHCP Snooping动态绑定表	配置DHCP Snooping功能后，DHCP主机动态获取IP地址时，设备根据DHCP服务器发送的DHCP回复的ACK报文动态生成。	适用于主机数较多且主机从DHCP服务器获取IP地址的场景。

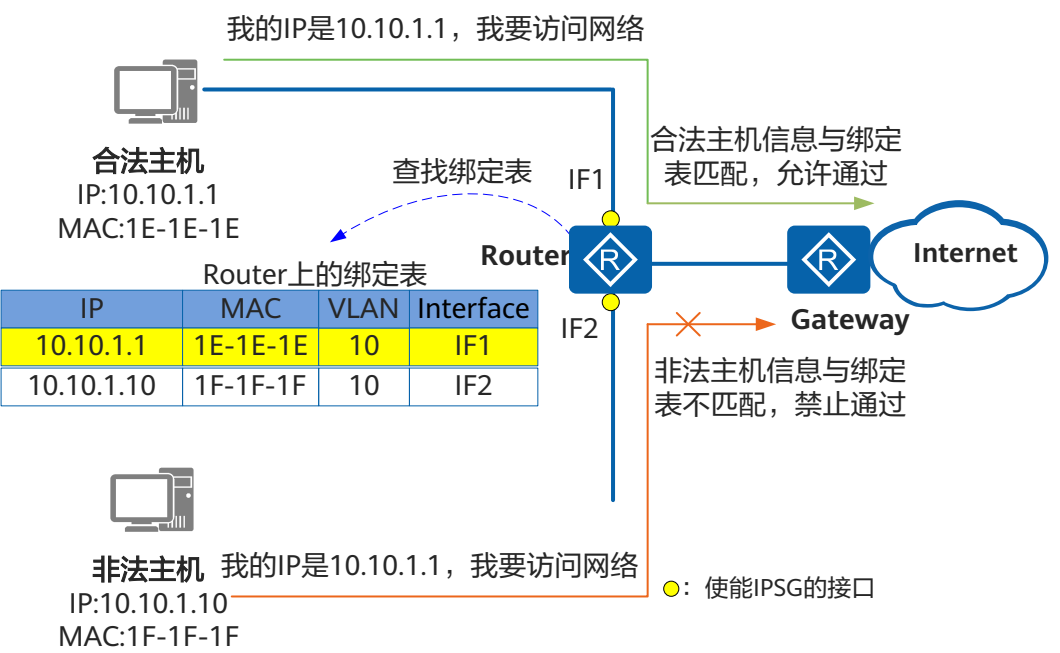
绑定表生成后，主机发送的报文，只有匹配绑定表才会允许通过，不匹配绑定表的报文都将被丢弃。缺省情况下，如果在没有绑定表的情况下使能了IPSP，设备将拒绝除DHCP请求报文外的所有IP报文。

说明

IPSP只匹配检查IP报文，对于ARP、PPPoE等非IP报文，IPSP不做匹配检查。

IPSP原理图如图14-2所示，非法主机仿冒合法主机的IP地址发送报文到达Router后，因报文和绑定表不匹配被Router丢弃。

图 14-2 IPSP 实现原理图



IPSP 中的接口角色

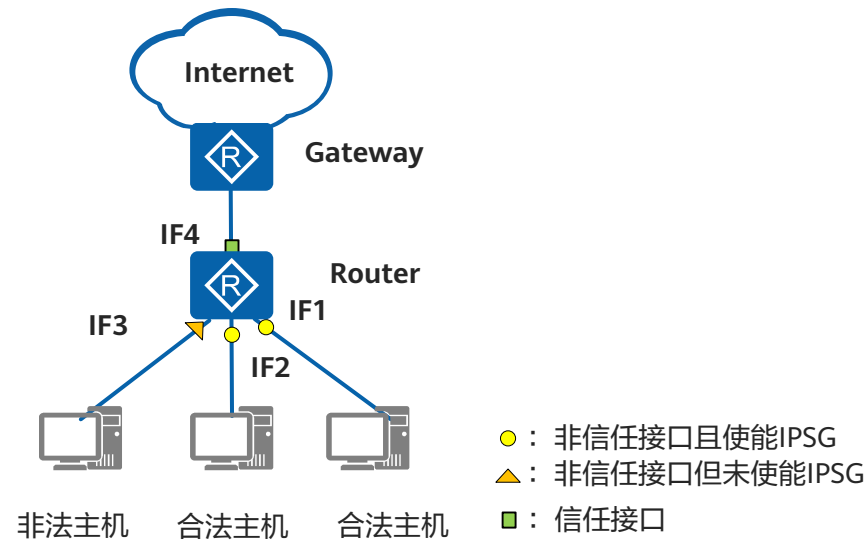
IPSP仅支持在二层物理接口或者VLAN上应用，且只对使能了IPSP功能的非信任接口进行检查。对于IPSP来说，缺省所有的接口均为非信任接口，信任接口由用户指定。

IPSG的信任接口/非信任接口也就是DHCP Snooping中的信任接口/非信任接口，信任接口/非信任接口同样适用于基于静态绑定表方式的IPSG。

IPSG中各接口角色如图14-3所示。其中：

- IF1和IF2接口为非信任接口且使能IPSG功能，从IF1和IF2接口收到的报文会执行IPSG检查。
- IF3接口为非信任接口但未使能IPSG功能，从IF3接口收到的报文不会执行IPSG检查，可能存在攻击。
- IF4接口为用户指定的信任接口，从IF4接口收到的报文也不会执行IPSG检查，但此接口一般不存在攻击。在DHCP Snooping的场景下，通常把与合法DHCP服务器直接或间接连接的接口设置为信任接口。

图 14-3 IPSG 中的接口角色示意图



IPSG 的过滤方式

IPSG的过滤主要检查：MAC地址、IP地址、VLAN ID、入接口四项。其中：

- 配置静态绑定时，四项需要全部进行匹配检查。
- 配置动态绑定时，检查项由用户设置。缺省状态是四项都进行匹配检查。常见的几种检查项如表14-2所示，其他组合类似，不一一列举。

表 14-2 IPSG 过滤方式

设置的检查项	含义
接口视图下	
接口+源IP地址	接口视图下，根据源IP地址对报文进行过滤，只有源IP地址和绑定表匹配，才允许报文通过。
接口+源MAC地址	接口视图下，根据源MAC地址对报文进行过滤，只有源MAC地址和绑定表匹配，才允许报文通过。

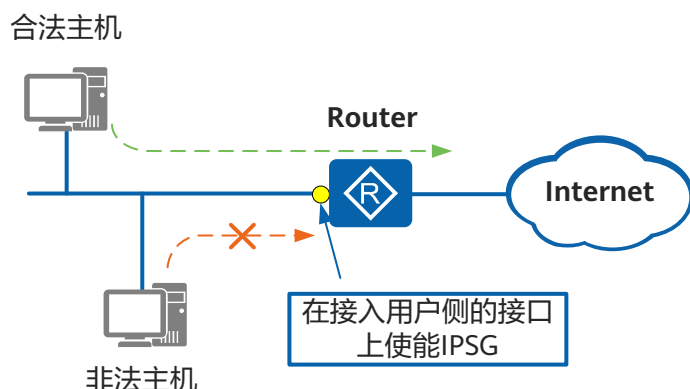
设置的检查项	含义
接口+源IP地址+源MAC地址	接口视图下，根据源IP和源MAC地址对报文进行过滤，只有源IP和源MAC地址都和绑定表匹配，才允许报文通过。
接口+源IP地址+VLAN	接口视图下，根据源IP地址和VLAN对报文进行过滤，只有源IP和VLAN都和绑定表匹配，才允许报文通过。
接口+源MAC地址+VLAN	接口视图下，根据源MAC地址和VLAN对报文进行过滤，只有源MAC地址和VLAN都和绑定表匹配，才允许报文通过。
接口+源IP地址+源MAC地址+VLAN	接口视图下，根据源IP、源MAC地址和VLAN对报文进行过滤，只有源IP、源MAC地址和VLAN都和绑定表匹配，才允许报文通过。
VLAN视图下	
VLAN+源IP地址	VLAN视图下，根据源IP地址对报文进行过滤，只有源IP地址和绑定表匹配，才允许报文通过。
VLAN+源MAC地址	VLAN视图下，根据源MAC地址对报文进行过滤，只有源MAC地址和绑定表匹配，才允许报文通过。
VLAN+源IP地址+源MAC地址	VLAN视图下，根据源IP和源MAC地址对报文进行过滤，只有源IP和源MAC地址都和绑定表匹配，才允许报文通过。
VLAN+源IP地址+接口	VLAN视图下，根据源IP地址和接口对报文进行过滤，只有源IP和接口都和绑定表匹配，才允许报文通过。
VLAN+源MAC地址+接口	VLAN视图下，根据源MAC地址和接口对报文进行过滤，只有源MAC地址和接口都和绑定表匹配，才允许报文通过。
VLAN+源IP地址+源MAC地址+接口	VLAN视图下，根据源IP、源MAC地址和接口对报文进行过滤，只有源IP、源MAC地址和接口都和绑定表匹配，才允许报文通过。

14.2.2 IPSG 应用在网络中的位置

IPSG一般应用在与用户直连的接入设备上，可以基于接口或者基于VLAN应用。

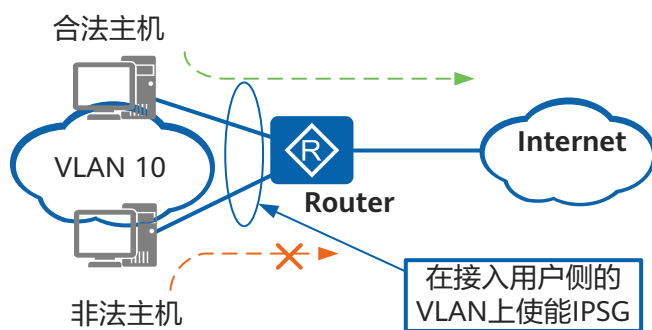
- 如图14-4所示，在接入用户侧的接口上应用IPSG，该接口接收的所有IP报文均进行IPSG检查。

图 14-4 基于接口使能 IPSPG



- 如图14-5所示，在接入用户侧的VLAN上应用IPSPG，属于该VLAN的所有接口接收到IP报文均进行IPSPG检查。

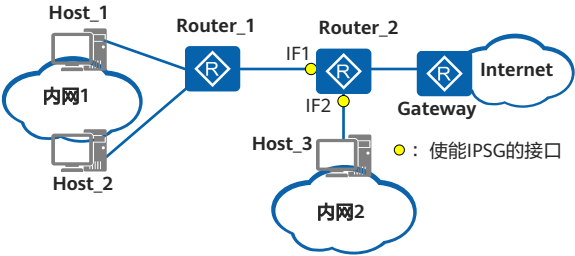
图 14-5 基于 VLAN 使能 IPSPG



如果与用户直连的接入设备不支持IPSPG功能，也可以在汇聚设备或核心设备上应用IPSPG，如图14-6所示。

- 假设接入内网1的Router_1不支持IPSPG功能，可以在Router_2上的IF1接口应用IPSPG（需要在Router_2上创建内网1内主机的绑定表）。但是由于Router_1没有IPSPG功能，所以从Router_1发送过来的报文是有可能存在IP欺骗攻击的，在Router_2的IF1接口上应用IPSPG可以把攻击隔绝在这里，使受攻击的范围减小到最小。
- 接入内网2的Router_2的IF2接口上也需要应用IPSPG功能，如果不应用，内网2内也可能存在IP地址欺骗攻击。

图 14-6 多路由器环境



14.2.3 IPSPG 与其他相关特性的比较

IPSG、动态ARP检测DAI（Dynamic ARP Inspection）、静态ARP、端口安全都是提高网络安全的技术，以下分别介绍[IPSG与DAI](#)、[IPSG与静态ARP](#)、[IPSG与端口安全](#)的主要区别。

IPSG 与 DAI

IPSG和DAI都是利用绑定表（静态绑定表或者DHCP Snooping绑定表）实现对报文过滤的技术。它们的主要区别如[表14-3](#)所示。

表 14-3 IPSG 与 DAI 的区别

特性	功能介绍	应用场景
IPSG	利用绑定表对IP报文进行过滤。设备会匹配检查接口上接收到的IP报文，只有匹配绑定表的IP报文才允许通过。	防止IP地址欺骗攻击。如防止非法主机盗用合法主机的IP地址，非法获取上网权限或者攻击网络。
DAI	利用绑定表对ARP报文进行过滤。设备会匹配检查接口上接收到的ARP报文，只有匹配绑定表的ARP报文才允许通过。	防御中间人攻击。中间人通过ARP欺骗，引导流量从自己这里经过，从而可以截获他人信息。

另外，IPSG无法避免地址冲突。例如，当非法主机在合法主机在线时盗用其IP地址，非法主机发送的ARP请求会广播到合法主机，从而产生地址冲突。所以，为了避免IP地址冲突，可以在部署IPSG的同时配置DAI。

有关DAI的详细介绍，请参见《AR300, AR700 配置指南-安全配置》中的[“ARP安全配置”](#)。

IPSG 与静态 ARP

IPSG（指基于静态绑定表的IPSG）和静态ARP都可以实现IP和MAC的绑定，它们的主要区别如[表14-4](#)所示。

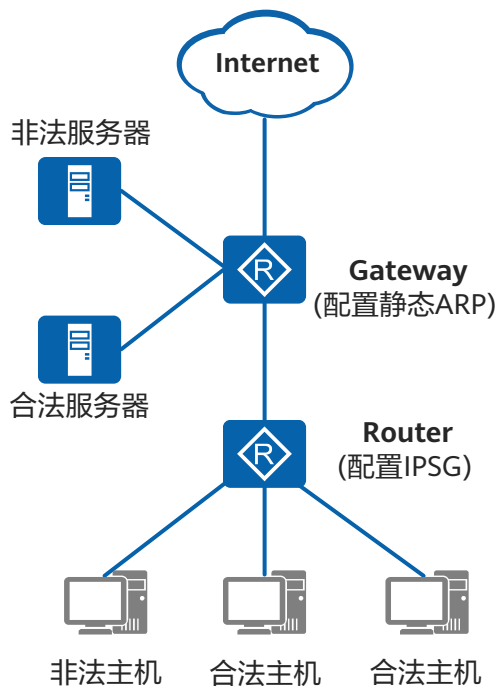
表 14-4 IPSG 和静态 ARP 的区别

特性	功能介绍	应用场景
IPSG	通过静态绑定表固定IP地址和MAC地址之间映射关系，设备会匹配检查接口上接收到的报文，只有匹配绑定表报文才允许通过。	一般部署在与用户直连的接入设备（也可以是汇聚或者核心设备）上，防止内网中的IP地址欺骗攻击，如非法主机仿冒合法主机的IP地址获取上网权限。
静态ARP	通过静态ARP表固定IP地址和MAC地址之间映射关系，静态ARP表项不会被动态刷新，设备根据静态ARP表转发接收到的报文。	一般部署在网关上，配置重要服务器的静态ARP表项，防止ARP欺骗攻击，保证主机和服务器之间的正常通信。

举例说明IPSG和静态ARP的应用，如图14-7所示。

- 通过在Router上配置IPSG，防止非法主机随意更改IP地址、仿冒合法主机取得上网权限。
- 通过在Gateway上配置服务器的静态ARP表项，防止非法服务器的ARP攻击、错误刷新ARP表项，导致主机无法和合法服务器通信。

图 14-7 IPSG 和静态 ARP 的应用组网图



IPSG和静态ARP的功能区别如下：

- **静态ARP防止不了IP地址欺骗攻击**

假设Router上未配置IPSG，而是在网关上配置了主机的静态ARP。当非法主机仿冒合法主机的IP地址访问Internet，报文转发过程如下：

- 非法主机发送的报文到达Router。
- Router将报文转发到Gateway。
- Gateway将报文发往Internet。
- Internet回程报文到达Gateway。
- Gateway根据目的IP地址（即仿冒的合法主机的IP地址）查找静态ARP表项，这个IP对应的MAC为合法主机的MAC，Gateway将封装后的报文发送给Router。
- Router根据目的MAC地址将报文转发到合法主机。

从过程来看，如果伪造的是合法主机的IP地址，配置静态ARP也能防止非法主机更改IP地址上网，但是会导致合法主机收到大量非法回应报文。如果合法主机在线时，非法主机不断构造并发送这种报文，则会对合法主机造成攻击。

如果非法主机仿冒的IP地址是一个未使用的IP地址，并且这个IP地址没有被添加到静态ARP表中，则会仿冒成功，回程报文可以到达非法主机。如果是希望通过配

置静态ARP来防止主机仿冒IP，那就需要把所有的IP（包括未使用的IP）都添加到静态ARP表项中，这样配置工作量会很大。

另外，因为是在网关上配置的静态ARP，所以Router所连接的网络内是存在IP欺骗攻击的，这个无法避免。

所以，如果是为了防止内网中的IP地址欺骗的攻击行为，建议在Router上配置IPSG更为合适。

● **IPSG防止不了ARP欺骗攻击**

假设Router上配置了IPSG，而网关上未配置主机的静态ARP。

- a. 非法主机伪造了合法主机的IP地址发送了虚假的ARP请求报文到达Router。
 - b. Router会转发到Gateway，导致Gateway将合法主机的ARP表项刷新成错误的表项（IP为合法主机的IP，MAC为非法主机的MAC）。
 - c. 当合法主机访问Internet，Internet回程报文将被转发到非法主机，导致合法主机也上不了网。
- 而且，从Internet主动发给合法主机的报文也会被非法主机截获，无法正常发送到合法主机。

为了解决这个问题，一种方法是在网关上同时配置主机的静态ARP，但是对于主机规模较大的场景下配置和维护会非常复杂。另一种方法是在Router上同时配置DAI功能，Router对于接口上收到的ARP报文也会匹配绑定表，对于非法的ARP报文同样会因与绑定表不匹配而被Router丢弃。非法ARP报文到达不了网关，也就更改不了ARP表项。

有关静态ARP的详细介绍，请参见《AR300, AR700 配置指南-IP业务配置》中的“ARP配置”。

IPSG 与端口安全

IPSG（指基于静态绑定表的IPSG）和端口安全都可以实现MAC地址和接口的绑定，它们的主要区别如表14-5所示。

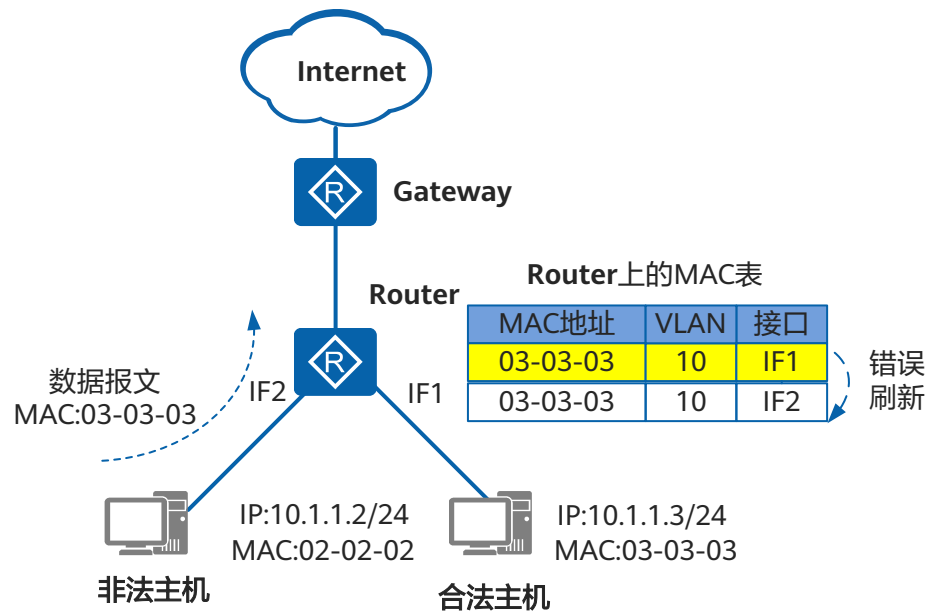
表 14-5 IPSG 与端口安全的区别

特性	功能介绍	应用场景
IPSG	通过在绑定表中固定MAC和接口的绑定关系，实现固定主机只能从固定接口上线，并且绑定表以外的非法MAC主机无法通过设备通信。 绑定表项需要手工配置，如果主机较多，配置工作量比较大。	绑定MAC和接口只是IPSG的一部分功能，IPSG能实现IP地址、MAC地址、VLAN和接口之间的任意绑定。它主要用来防止IP地址欺骗攻击，如防止非法主机盗用合法主机的IP地址，非法获取上网权限或者攻击网络。
端口安全	通过将接口学习到的指定数量的动态MAC地址转换为安全MAC地址，以固定MAC表项，实现固定主机只能从固定接口上线，并且MAC表以外的非法MAC主机无法通过设备通信。 安全MAC地址是动态生成的，无需手工配置。	防止非法主机接入，还可以控制接入主机的数量，比较适合于主机较多的场景。

因此，如果只是希望阻止非法MAC通过设备通信，并且在主机较多的环境下，配置端口安全更合适。

另外，IPSPG不会固定MAC表项，无法防止MAC表被错误刷新而产生MAC漂移问题。如图14-8所示，非法主机伪造合法主机的MAC地址发送数据（例如发送伪造的ARP报文）到达Router，会错误刷新MAC表，导致非法主机截获发往合法主机的报文。

图 14-8 MAC 表错误刷新示意图



此时，可设置根据绑定表生成Snooping类型的MAC表项（也是一种安全MAC），解决上述问题。

有关端口安全的详细介绍，请参见《AR300, AR700 配置指南-安全配置》中的“[端口安全配置](#)”。

由此可见，IPSPG、DAI、静态ARP、端口安全是针对不同需求的，它们都有自己独特的价值。为了网络更加安全，建议综合考虑，灵活应用。

14.3 IPSPG 应用场景

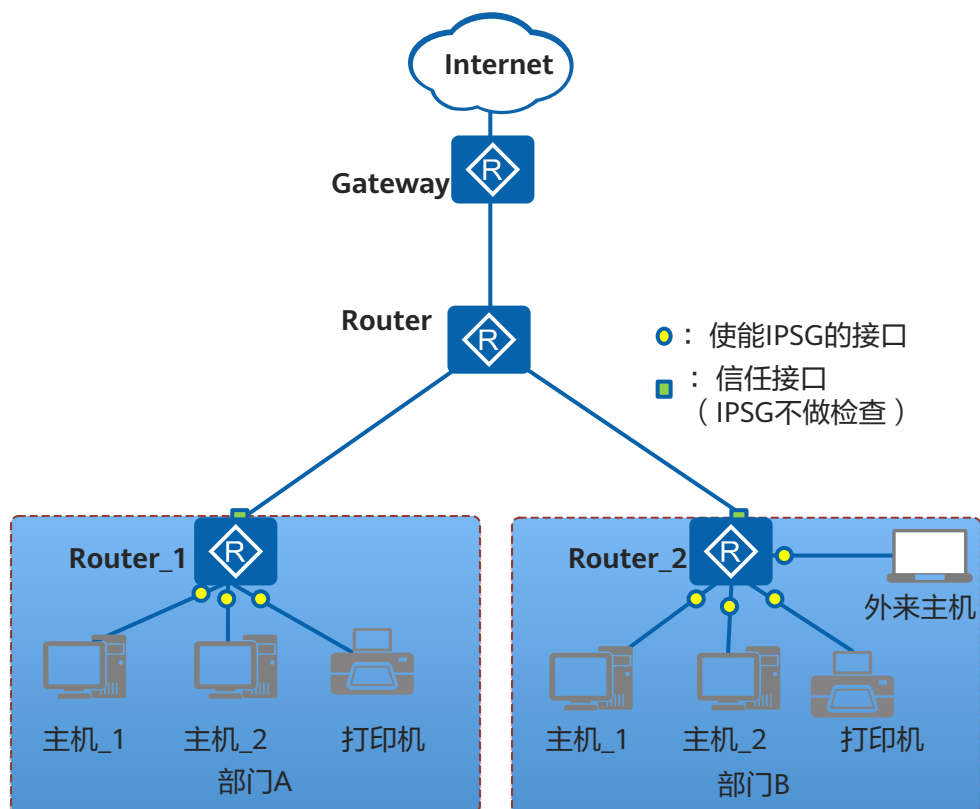
介绍IPSPG在园区网中的常见应用，如通过IPSPG防止主机私自更改IP地址上网、限制非法主机接入网络。

某园区网如图14-9所示，针对不同的园区，可能会有不同地址规划。一般情况下：

- 在园区规模较小时，园区内主机和打印机会使用静态的IP地址；
- 在园区规模稍大时，园区内主机会通过DHCP方式获取IP地址，而部分打印机等使用静态的IP地址。

在园区网接入用户的设备Router_1、Router_2上部署IPSPG，实现如下场景应用。

图 14-9 IPSG 典型应用组网图



场景 1：通过 IPSG 防止主机私自更改 IP 地址

- 主机只能使用DHCP Server分配的IP地址或者管理员配置的静态地址，随意更改IP地址后无法访问网络，防止主机非法取得上网权限。
- 打印机配置的静态IP地址只供打印机使用，防止主机通过仿冒打印机的IP地址访问网络。

场景 2：通过 IPSG 限制非法主机接入（针对 IP 地址是静态分配的环境）

- 固定的主机只能从固定的接口接入，不能随意更换接入位置，满足基于接口限速的目的。
- 外来人员自带电脑不能随意接入内网，防止内网资源泄露。

对于IP地址是DHCP动态分配的环境，一般是通过NAC认证（比如Portal认证等）功能实现限制非法主机接入。

14.4 IPSG 配置注意事项

介绍配置IPSG的注意事项。

涉及网元

无需其他网元配合。

License 支持

IPSG特性是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

对于设备上的单板而言，仅8FE1GE单板支持此功能。

特性依赖和限制

路由器只支持三层流量检测。

14.5 IPSG 缺省配置

介绍IPSG的缺省配置，实际应用的配置可以基于缺省配置进行修改。

IPSG的缺省配置如表14-6所示。

表 14-6 IPSG 缺省配置

参数	缺省值
IP报文检查功能	未使能
IP报文检查选项	源IP地址、源MAC地址、VLAN和接口

14.6 配置 IPSG

分别介绍基于静态绑定表和动态绑定表两种方式下的IPSG的配置过程。

14.6.1 配置基于静态绑定表的 IPSG

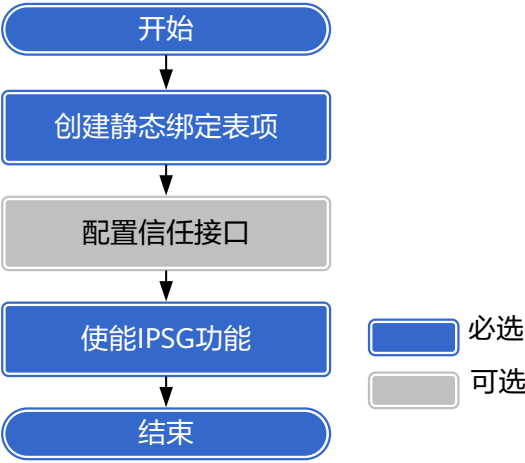
配置基于静态绑定表的IPSG，实现对非信任接口上接收的IP报文进行过滤控制，防止恶意主机盗用合法主机的IP地址来仿冒合法主机，获取网络资源的使用权限。

背景信息

该方式适用于局域网络中主机数较少且主机使用静态配置IP地址的情况。

配置流程

图 14-10 基于静态绑定表的 IPSG 配置流程图



请在接入用户的设备上进行如下配置。

操作步骤

步骤1 创建静态绑定表项

静态绑定表项包括IPv4和IPv6两种绑定表项，请根据网络环境选择配置。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**user-bind static { { ip-address | ipv6-address } { start-ip [to end-ip] } &<1-10> | mac-address mac-address } * [interface interface-type interface-number] [vlan vlan-id [ce-vlan ce-vlan-id]]**，配置静态用户绑定表项。

缺省情况下，不存在静态绑定表。

说明

IPSG按照静态绑定表项进行完全匹配，即静态绑定表项包含几项就检查几项。请确保所创建的绑定表是正确且完整的，主机发送的报文只有匹配绑定表才会允许通过，不匹配绑定表的报文都将被丢弃。

设备支持将多个IP地址（段）做批量绑定，例如多个IP批量绑定到同一个接口或同一个MAC。

- 如果这些IP地址不是连续的，可以重复输入1~10个start-ip地址。例如执行命令**user-bind static ip-address 192.168.1.2 192.168.1.5 192.168.1.12 interface ethernet 2/0/0**，将多个IP地址绑定到同一个接口。
- 如果这些IP地址是连续的，可以重复输入1~10个start-ip to end-ip的地址段。需要注意的是，采用关键字to输入的区间不能有交叉。例如执行命令**user-bind static ip-address 172.16.1.1 to 172.16.1.4 mac-address 00e0-fc01-0101**，将多个IP地址绑定到同一个MAC地址。

如果绑定表创建错误或者已绑定主机的网络权限变更，需要删除某些静态表项，请执行命令**undo user-bind static [interface interface-type interface-number | { ip-address | ipv6-address } { start-ip [to end-ip] } &<1-10> | mac-address mac-address | vlan vlan-id [ce-vlan ce-vlan-id]] ***。

步骤2 （可选）配置信任接口

主机是静态地址分配的环境，一般不需要配置信任接口。但当上行接口同时在使能IPSG功能的VLAN内，则需要将上行口配置成信任接口，否则回程报文会因匹配不到绑定表而被丢弃，导致业务不通。故障详述请参见[14.8.3 IPSG中未配置上行信任接口导致业务不通](#)。配置为信任接口后，从信任接口收到的报文不做匹配检查直接允许通过，可以避免上述问题的发生。

1. 执行命令**dhcp enable**，全局使能DHCP功能。
缺省情况下，没有全局使能DHCP功能。
2. 执行命令**dhcp snooping enable**，全局使能DHCP Snooping功能。
缺省情况下，没有全局使能DHCP Snooping功能。
3. 配置信任接口。
 - 当配置基于VLAN内的信任接口时，执行命令**dhcp snooping trusted interface interface-type interface-number**，配置加入该VLAN的接口为信任状态。
 - 当配置基于接口的信任状态时，执行命令**dhcp snooping trusted**，配置接口为信任状态。

缺省情况下，使能DHCP Snooping功能后，接口为非信任状态。

步骤3 使能IPSG功能

绑定表创建后，IPSG并未生效，只有在指定接口（接入用户侧的接口）或在指定VLAN上使能IPSG后才生效。

- 基于接口使能IPSG：该接口接收的所有的报文均进行IPSG检查。如果用户只希望在某些不信任的接口上进行IPSG检查，而信任其他接口，可以选择此方式。并且，当接口属于多个VLAN时，基于接口使能IPSG更方便，无需在每个VLAN上使能。
- 基于VLAN使能IPSG：属于该VLAN的所有接口接收的报文均进行IPSG检查。如果用户只希望在某些不信任VLAN上进行IPSG检查，而信任其他VLAN，可以选择此方式。并且，当多个接口属于相同的VLAN时，基于VLAN使能IPSG更方便，无需在每个接口上使能。

说明

- 接口上使能仅对该接口生效，其它接口不会执行IPSG检查。
 - VLAN上使能仅对该VLAN生效，其它VLAN不会执行IPSG检查。
1. 进入接口或VLAN视图。
 - 执行命令**interface interface-type interface-number**，进入接口视图。
 - 执行命令**vlan vlan-id**，进入VLAN视图。
 2. 执行命令**ip source check user-bind enable**，使能接口或者VLAN的IP报文检查功能。
缺省情况下，接口和VLAN上未使能IP报文检查功能。

----结束

检查配置结果

- 执行命令**display ip source check user-bind { vlan vlan-id | interface interface-type interface-number }**，查看IPSG的配置信息。

- 执行命令**display dhcp static user-bind** { { **interface** *interface-type interface-number* | **ip-address** *ip-address* | **mac-address** *mac-address* | **vlan** *vlan-id* } * | **all** } [**verbose**]，查看IPv4静态绑定表信息。
- 执行命令**display dhcpv6 static user-bind** { { **interface** *interface-type interface-number* | **ipv6-address** *ipv6-address* | **mac-address** *mac-address* | **vlan** *vlan-id* } * | **all** } [**verbose**]，查看IPv6静态绑定表信息。

14.6.2 配置基于动态绑定表的 IPSG

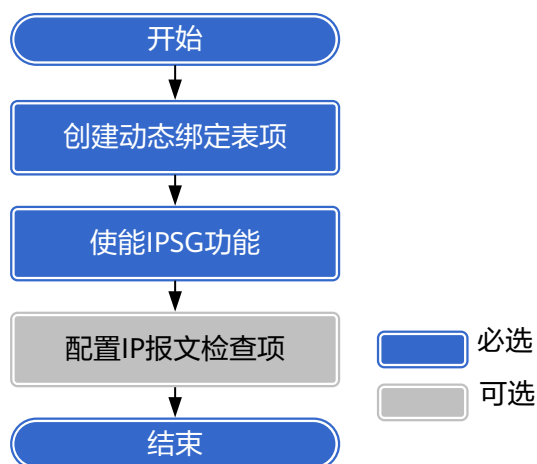
配置基于动态绑定表的IPSG，实现对非信任接口上接收的IP报文进行过滤控制，防止恶意主机盗用合法主机的IP地址来仿冒合法主机，获取网络资源的使用权限。

背景信息

该方式适用于局域网络中主机较多，或者主机使用DHCP动态获取IP地址的情况。

配置流程

图 14-11 基于动态绑定表的 IPSG 配置流程图



请在接入用户的设备上进行如下配置。

操作步骤

步骤1 创建动态绑定表项

动态绑定表项包括IPv4和IPv6两种绑定表项，请根据网络环境选择配置。

通过DHCP方式获取IP地址的IPv4或者IPv6主机，可以配置DHCP Snooping生成DHCP Snooping动态绑定表项

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**dhcp enable**，使能DHCP功能。
缺省情况下，未使能DHCP功能。
3. 执行命令**dhcp snooping enable**，全局使能DHCP Snooping功能。
缺省情况下，全局未使能DHCP Snooping功能。

4. 进入VLAN或者接口视图。
 - 执行命令**vlan** *vlan-id*, 进入VLAN视图。
 - 执行命令**interface** *interface-type interface-number*, 进入接口视图。
5. 执行命令**dhcp snooping enable**, 使能VLAN或者接口的DHCP Snooping功能。
缺省情况下, VLAN和接口下未使能DHCP Snooping功能。

说明

为使设备能够获取到用户的绑定表项, 在接口或VLAN下使能DHCP Snooping功能之前, 需确保已在该接口或VLAN对应的VLANIF口上使能了DHCP Relay或DHCP Server功能。

6. 配置信任接口, 以下任务二选一。
 - 在VLAN视图下执行命令**dhcp snooping trusted interface** *interface-type interface-number*, 配置加入该VLAN的接口为信任状态。
 - 在接口视图下执行命令**dhcp snooping trusted**, 配置该接口为信任状态。
缺省情况下, 使能DHCP Snooping功能后, 接口为非信任状态。

说明

一般将与服务器直接或间接相连的接口配置为信任接口。在使能DHCP Snooping功能并配置信任接口之后, 用户侧接口根据DHCP ACK报文自动生成动态绑定表。

有关DHCP Snooping的详细配置, 请参见《AR300, AR700 配置指南-安全配置》中的“[13 DHCP Snooping配置](#)”。

步骤2 使能IPSG功能

绑定表创建后, IPSG并未生效, 只有在指定接口（接入用户侧的接口）或在指定VLAN上使能IPSG后才生效。

- 基于接口使能IPSG: 该接口接收的所有的报文均进行IPSG检查。如果用户只希望在某些不信任的接口上进行IPSG检查, 而信任其他接口, 可以选择此方式。并且, 当接口属于多个VLAN时, 基于接口使能IPSG更方便, 无需在每个VLAN上使能。
- 基于VLAN使能IPSG: 属于该VLAN的所有接口接收的报文均进行IPSG检查。如果用户只希望在某些不信任VLAN上进行IPSG检查, 而信任其他VLAN, 可以选择此方式。并且, 当多个接口属于相同的VLAN时, 基于VLAN使能IPSG更方便, 无需在每个接口上使能。

说明

- 接口上使能仅对该接口生效, 其它接口不会执行IPSG检查。
- VLAN上使能仅对该VLAN生效, 其它VLAN不会执行IPSG检查。

1. 进入接口或VLAN视图。
 - 执行命令**interface** *interface-type interface-number*, 进入接口视图。
 - 执行命令**vlan** *vlan-id*, 进入VLAN视图。
2. 执行命令**ip source check user-bind enable**, 使能接口或者VLAN的IP报文检查功能。
缺省情况下, 接口和VLAN上未使能IP报文检查功能。

步骤3 （可选）配置IP报文检查项

- 如果基于VLAN使能IPSG, 在VLAN视图下执行命令**ip source check user-bind check-item { ip-address | mac-address | interface } ***, 配置IP报文检查项。

- 如果基于接口使能IPSG，在接口视图下执行命令**ip source check user-bind check-item { ip-address | mac-address | vlan } ***，配置IP报文检查项。

缺省情况下，IP报文检查项包括IP地址、MAC地址、VLAN和接口。如果用户信任某些检查项，或者某些项目不固定（例如客户端的流量可能从不同的接口进入设备），可以选择配置此步骤。一般采用缺省值。

----结束

检查配置结果

- 执行命令**display ip source check user-bind { vlan *vlan-id* | interface *interface-type interface-number* }**，查看IPSG的配置信息。
- 查看生成的动态绑定表项及状态
 - 执行命令**display dhcp snooping user-bind { { interface *interface-type interface-number* | ip-address *ip-address* | mac-address *mac-address* | vlan *vlan-id* } * | all } [verbose]**，查看DHCP Snooping动态绑定表信息。
 - 执行命令**display dhcpv6 snooping user-bind { { interface *interface-type interface-number* | ipv6-address *ipv6-address* | mac-address *mac-address* | vlan *vlan-id* } * | all } [verbose]**，查看DHCPv6 Snooping动态绑定表信息。

14.7 IPSG 配置举例

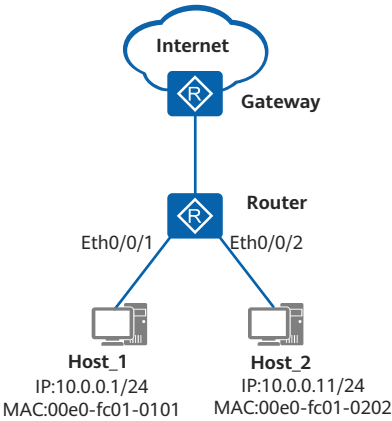
通过示例介绍IPSG如何防止主机私自更改IP地址、避免非法主机访问内网，提供组网图、配置步骤和配置文件等。

14.7.1 配置 IPSG 防止主机仿冒其他主机 IP 地址示例（静态绑定）

组网需求

如图14-12所示，Host通过Router接入网络，Gateway为企业出口网关，各Host均使用静态配置的IP地址。管理员希望Host使用管理员分配的固定IP地址上网，不允许仿冒其他主机的IP地址非法获取网络访问权限。

图 14-12 配置 IPSG 防止主机仿冒其他主机的 IP 地址（静态绑定）组网图



配置思路

采用如下的思路在Router上配置IPSG功能，实现上述需求。

1. 在Router上配置Host_1和Host_2的静态绑定表，固定IP和MAC的绑定关系。

2. 在Router连接用户主机的接口使能IPSPG，实现Host只能使用管理员分配的固定IP地址上网。

操作步骤

步骤1 创建Host_1和Host_2的静态绑定表项

```
<Huawei> system-view
[Huawei] sysname Router
[Router] user-bind static ip-address 10.0.0.1 mac-address 00e0-fc01-0101
[Router] user-bind static ip-address 10.0.0.11 mac-address 00e0-fc01-0202
```

步骤2 使能IPSPG功能

在连接Host_1的Eth0/0/1接口使能IPSPG功能。

```
[Router] interface ethernet 0/0/1
[Router-Ethernet0/0/1] ip source check user-bind enable
[Router-Ethernet0/0/1] quit
```

在连接Host_2的Eth0/0/2接口使能IPSPG功能。

```
[Router] interface ethernet 0/0/2
[Router-Ethernet0/0/2] ip source check user-bind enable
[Router-Ethernet0/0/2] quit
```

步骤3 验证配置结果

在Router上执行display dhcp static user-bind all命令，可以查看静态绑定表信息。

```
[Router] display dhcp static user-bind all
DHCP static Bind-table:
Flags:O - outer vlan ,I - inner vlan ,P - Vlan-mapping
IP Address          MAC Address      VSI/VLAN(O/I/P) Interface
-----
10.0.0.1            00e0-fc01-0101  -- /-- /--  --
10.0.0.11          00e0-fc01-0202  -- /-- /--  --
-----
Print count:      2      Total count:      2
```

Host_1和Host_2使用管理员分配的固定IP地址可以正常访问网络，更改IP地址后无法访问网络。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
user-bind static ip-address 10.0.0.1 mac-address 00e0-fc01-0101
user-bind static ip-address 10.0.0.11 mac-address 00e0-fc01-0202
#
interface Ethernet0/0/1
ip source check user-bind enable
#
interface Ethernet0/0/2
ip source check user-bind enable
#
return
```

相关信息

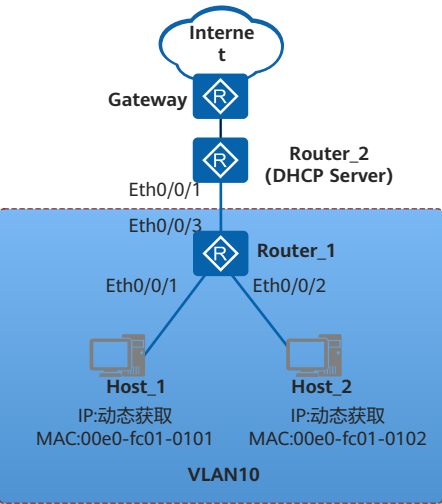
视频：[AR系列路由器对应静态分配地址的用户，配置IP地址、MAC地址和端口的绑定](#)

14.7.2 配置 IPSG 防止主机仿冒其他主机 IP 地址示例（DHCP Snooping 动态绑定）

组网需求

如图14-13所示，Host通过Router_1接入网络，Router_2作为DHCP Server为Host动态分配IP地址，Gateway为企业出口网关。管理员希望Host使用动态分配的地址，不允许私自配置静态IP地址，如果私自指定IP地址将无法访问网络。

图 14-13 配置 IPSG 防止主机仿冒其他主机 IP 地址（DHCP Snooping 动态绑定）组网图



配置思路

采用如下的思路配置IPSPG功能，实现上述需求。

1. 在Router_2上配置DHCP Server功能（假设地址池为10.1.1.0/24），为Host动态分配IP地址。
2. 在Router_1上配置DHCP Snooping功能，保证Host从合法的DHCP Server获取IP地址，同时生成DHCP Snooping动态绑定表，记录Host的IP地址、MAC地址、VLAN、接口的绑定关系。
3. 在Router_1连接Host的VLAN上使能IPSPG功能，防止Host通过私自配置IP地址的方式访问网络。

操作步骤

步骤1 在Router_2上配置DHCP Server功能

```
<Huawei> system-view
[Huawei] sysname Router_2
[Router_2] vlan batch 10
[Router_2] interface ethernet 0/0/1
[Router_2-Ethernet0/0/1] port link-type trunk
[Router_2-Ethernet0/0/1] port trunk allow-pass vlan 10
[Router_2-Ethernet0/0/1] quit
[Router_2] dhcp enable
[Router_2] ip pool 10
[Router_2-ip-pool-10] network 10.1.1.0 mask 24
[Router_2-ip-pool-10] gateway-list 10.1.1.1
[Router_2-ip-pool-10] quit
[Router_2] interface vlanif 10
[Router_2-Vlanif10] ip address 10.1.1.1 255.255.255.0
[Router_2-Vlanif10] dhcp select global
[Router_2-Vlanif10] quit
```

步骤2 在Router_1上配置DHCP Snooping功能

配置各接口所属VLAN。

```
<Huawei> system-view
[Huawei] sysname Router_1
[Router_1] vlan batch 10
[Router_1] interface ethernet 0/0/1
[Router_1-Ethernet0/0/1] port link-type access
[Router_1-Ethernet0/0/1] port default vlan 10
[Router_1-Ethernet0/0/1] quit
[Router_1] interface ethernet 0/0/2
[Router_1-Ethernet0/0/2] port link-type access
[Router_1-Ethernet0/0/2] port default vlan 10
[Router_1-Ethernet0/0/2] quit
[Router_1] interface ethernet 0/0/3
[Router_1-Ethernet0/0/3] port link-type trunk
[Router_1-Ethernet0/0/3] port trunk allow-pass vlan 10
[Router_1-Ethernet0/0/3] quit
```

使能DHCP Snooping功能，并将连接DHCP Server的Eth0/0/3接口配置为信任接口。

```
[Router_1] dhcp enable
[Router_1] dhcp snooping enable
[Router_1] vlan 10
[Router_1-vlan10] dhcp snooping enable
[Router_1-vlan10] dhcp snooping trusted interface ethernet 0/0/3
```

步骤3 在Router_1的VLAN10上使能IPSPG功能

```
[Router_1-vlan10] ip source check user-bind enable
[Router_1-vlan10] quit
```

步骤4 验证配置结果

Host上线后，在Router_1上执行**display dhcp snooping user-bind all**命令，可以查看Host的动态绑定表信息。

```
[Router_1] display dhcp snooping user-bind all
DHCP Dynamic Bind-table:
Flags:O - outer vlan ,I - inner vlan ,P - Vlan-mapping
IP Address      MAC Address    VSI/VLAN(O/I/P) Interface    Lease
-----
10.1.1.254      00e0-fc01-0101 -- /10 /--  Eth0/0/1    2014.08.17-07:31
10.1.1.253      00e0-fc01-0102 -- /10 /--  Eth0/0/2    2014.08.17-07:34
-----
print count:    2    total count:    2
```

Host使用DHCP服务器动态分配的IP地址可以正常访问网络，将Host更改为与动态获得的IP地址不一样的静态IP地址后无法访问网络。

----结束

配置文件

- Router_1的配置文件

```
#
sysname Router_1
#
vlan batch 10
#
dhcp enable
#
dhcp snooping enable
#
vlan 10
  dhcp snooping enable
  dhcp snooping trusted interface Ethernet0/0/3
  ip source check user-bind enable
#
interface Ethernet0/0/1
  port link-type access
  port default vlan 10
#
interface Ethernet0/0/2
  port link-type access
  port default vlan 10
#
interface Ethernet0/0/3
  port link-type trunk
  port trunk allow-pass vlan 10
#
return
```

- Router_2的配置文件

```
#
sysname Router_2
#
vlan batch 10
#
dhcp enable
#
ip pool 10
  gateway-list 10.1.1.1
  network 10.1.1.0 mask 255.255.255.0
#
interface Vlanif10
  ip address 10.1.1.1 255.255.255.0
  dhcp select global
#
```



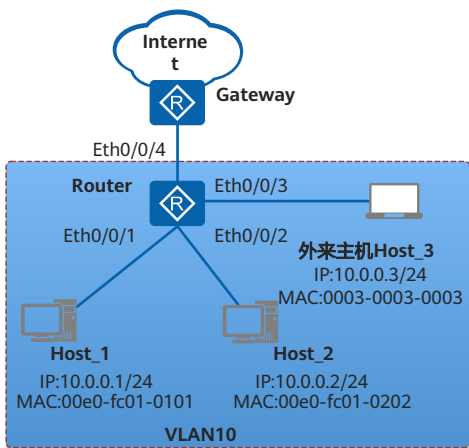
```
interface Ethernet0/0/1
 port link-type trunk
 port trunk allow-pass vlan 10
#
return
```

14.7.3 配置 IPSG 限制非法主机访问内网示例（静态绑定）

组网需求

如图14-14所示，Host通过Router接入网络，Gateway为企业出口网关，各Host均使用静态配置的IP地址。管理员在Router上做了接口限制，希望Host使用管理员分配的固定IP地址、从固定的接口上线。同时为了安全考虑，不允许外来人员的电脑随意接入内网。

图 14-14 配置 IPSG 限制非法主机访问内网（静态绑定）组网图



配置思路

采用如下的思路在Router上配置IPSG功能，实现上述需求。

- 1. 在Router上配置各接口所属VLAN。

2. 在Router上创建Host_1和Host_2的静态绑定表项，固定IP地址、MAC地址、接口的绑定关系。
3. 在Router上配置Eth0/0/4为信任接口，从该接口收到的报文不执行IPSG检查，防止从Gateway回程报文被丢弃。
4. 在Router连接用户主机的VLAN上使能IPSG功能，实现Host_1、Host_2使用固定的IP地址、从固定的接口上线，并且外来主机Host_3无法随意接入内网。

操作步骤

步骤1 配置各接口所属VLAN

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 10
[Router] interface ethernet 0/0/1
[Router-Ethernet0/0/1] port link-type access
[Router-Ethernet0/0/1] port default vlan 10
[Router-Ethernet0/0/1] quit
[Router] interface ethernet 0/0/2
[Router-Ethernet0/0/2] port link-type access
[Router-Ethernet0/0/2] port default vlan 10
[Router-Ethernet0/0/2] quit
[Router] interface ethernet 0/0/3
[Router-Ethernet0/0/3] port link-type access
[Router-Ethernet0/0/3] port default vlan 10
[Router-Ethernet0/0/3] quit
[Router] interface ethernet 0/0/4
[Router-Ethernet0/0/4] port link-type trunk
[Router-Ethernet0/0/4] port trunk allow-pass vlan 10
[Router-Ethernet0/0/4] quit
```

步骤2 创建Host_1和Host_2的静态绑定表项

```
[Router] user-bind static ip-address 10.0.0.1 mac-address 00e0-fc01-0101 interface ethernet 0/0/1
[Router] user-bind static ip-address 10.0.0.2 mac-address 00e0-fc01-0202 interface ethernet 0/0/2
```

步骤3 配置上行口Eth0/0/4为信任接口

```
[Router] dhcp enable
[Router] dhcp snooping enable
[Router] interface ethernet 0/0/4
[Router-Ethernet0/0/4] dhcp snooping trusted
[Router-Ethernet0/0/4] quit
```

步骤4 在连接Host的VLAN10上使能IPSG功能

```
[Router] vlan 10
[Router-vlan10] ip source check user-bind enable
[Router-vlan10] quit
```

步骤5 验证配置结果

在Router上执行**display dhcp static user-bind all**命令，可以查看Host_1和Host_2的绑定表信息。

```
[Router] display dhcp static user-bind all
DHCP static Bind-table:
Flags:O - outer vlan ,I - inner vlan ,P - Vlan-mapping
IP Address          MAC Address      VSI/VLAN(O/I/P) Interface
-----
10.0.0.1             00e0-fc01-0101  -- /-- /--  Eth0/0/1
10.0.0.2             00e0-fc01-0202  -- /-- /--  Eth0/0/2
-----
Print count:        2      Total count:      2
```

Host_1和Host_2可以正常访问网络，更换IP地址或者从其他接口接入后将无法访问网络。

将一台外来主机Host_3配置10.0.0.3的IP地址并接入接口Eth0/0/3后，Host_3仍无法访问网络，说明外来主机不能通过随意设置IP地址访问内网。如果Host_3需要访问内网资源，需要管理员在静态绑定表中添加Host_3的表项。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
vlan batch 10
#
dhcp enable
#
dhcp snooping enable
user-bind static ip-address 10.0.0.1 mac-address 00e0-fc01-0101 interface Ethernet0/0/1
user-bind static ip-address 10.0.0.2 mac-address 00e0-fc01-0202 interface Ethernet0/0/2
#
vlan 10
ip source check user-bind enable
#
interface Ethernet0/0/1
port link-type access
port default vlan 10
#
interface Ethernet0/0/2
port link-type access
port default vlan 10
#
interface Ethernet0/0/3
port link-type access
port default vlan 10
#
interface Ethernet0/0/4
port link-type trunk
port trunk allow-pass vlan 10
dhcp snooping trusted
#
return
```

14.8 IPSG 常见配置错误

介绍IPSG常见的配置错误导致的故障问题（如接口未使能导致IPSG业务不生效），并给出正确的配置。

14.8.1 接口或 VLAN 上未使能导致 IPSG 功能不生效

故障现象

已创建并生成了绑定表，但IPSG功能未能生效。

操作步骤

步骤1 检查IPSG功能是否在指定接口或者指定VLAN上使能。

绑定表创建后，IPSG并未生效，只有在指定接口或在指定VLAN上使能IPSG后功能才生效。

接口或VLAN方式只选择其一即可，两者的区别在于：

- 基于接口使能IPSG：该接口接收的所有的报文均进行IPSG检查。如果用户只希望在某些不信任的接口上进行IPSG检查，而信任其他接口，可以选择此方式。并且，当接口属于多个VLAN时，基于接口使能IPSG更方便，无需在每个VLAN上使能。
- 基于VLAN使能IPSG：属于该VLAN的所有接口接收的报文均进行IPSG检查。如果用户只希望在某些不信任VLAN上进行IPSG检查，而信任其他VLAN，可以选择此方式。并且，当多个接口属于相同的VLAN时，基于VLAN使能IPSG更方便，无需在每个接口上使能。

另外，需要注意的是，IPSG仅在使能的接口或使能的VLAN上生效，未使能的接口和VLAN上不会执行IPSG检查。所以如果是部分的接口或VLAN上IPSG不生效，很可能是这部分接口或VLAN上未使能IPSG导致的。

步骤2 执行命令**display ip source check user-bind { vlan *vlan-id* | interface *interface-type interface-number* }**，查看接入用户的接口或VLAN上是否使能了IPSG。

步骤3 如果接口未使能IPSG，继续在VLAN视图下执行命令**display this**，查看接入用户的VLAN上是否使能了IPSG。

步骤4 如果接口和VLAN上均未使能IPSG功能（显示信息中无“ip source check user-bind enable”），请在接口视图或者VLAN视图下执行命令**ip source check user-bind enable**，使能IPSG功能。

----结束

14.8.2 静态绑定表项错误导致合法主机上不了网

故障现象

已创建静态绑定表且使能了IPSG功能，但合法主机却上不了网。

操作步骤

步骤1 检查绑定表信息是否正确

执行命令**display dhcp static user-bind { { interface *interface-type interface-number* | ip-address *ip-address* | mac-address *mac-address* | vlan *vlan-id* } * | all }**，查看静态绑定表信息。

需要上网的合法主机却上不了网，可能因为绑定表信息不正确导致。

- 如果合法主机信息不在绑定表中，请添加该主机的绑定表项。只有绑定表中存在该主机的表项，设备才允许主机的报文通过。
- 如果需要合法主机信息在绑定表中，请查看该条表项的MAC地址是否正确，是否因主机更换了网卡未及时刷新绑定表导致。如果是，请删除该条绑定表项并重新添加。
- 如果合法主机信息在绑定表中，请查看该条表项是否包含VLAN信息。如果包含VLAN信息，请执行命令**display vlan**查看主机接入的接口是否加入该VLAN中。只有该接口加入了这个VLAN，设备才允许主机的报文通过。

步骤2 添加绑定表

执行命令 `user-bind static { { ip-address | ipv6-address } { start-ip [ to end-ip ] } &<1-10> | mac-address mac-address } * [ interface interface-type interface-number ] [ vlan vlan-id [ ce-vlan ce-vlan-id ] ]`

步骤3 删除绑定表

执行命令 `undo user-bind static [ interface interface-type interface-number | { ip-address | ipv6-address } { start-ip [ to end-ip ] } &<1-10> | mac-address mac-address | vlan vlan-id [ ce-vlan ce-vlan-id ] ] *`

----结束

14.8.3 IPSPG 中未配置上行信任接口导致业务不通

故障现象

VLAN内使能IPSPG后所有主机访问不了外网，业务不通。

操作步骤

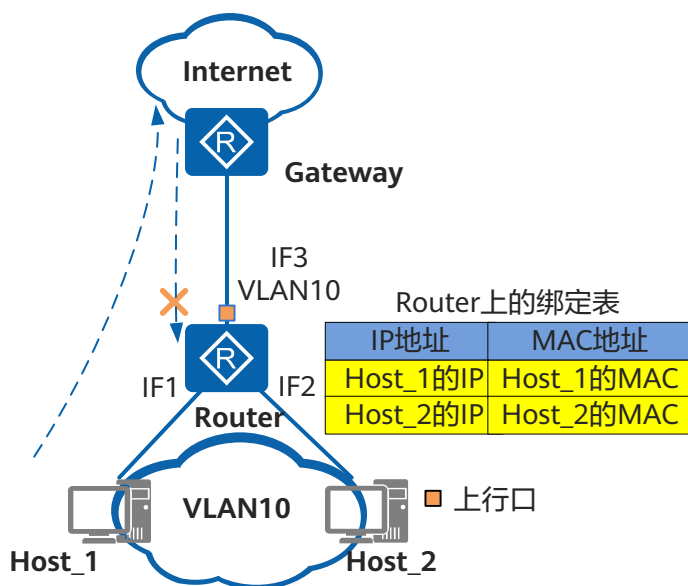
步骤1 检查上行口是否在使能IPSPG功能的VLAN内

如果上行接口同时在使能IPSPG功能的VLAN内，则需要将上行接口配置成信任接口，否则回程报文会因匹配不到绑定表而被丢弃，导致业务不通。

如图14-15所示，Host_1和Host_2同属于VLAN10，IF3允许VLAN10报文通过。在Router上创建了Host_1和Host_2的静态绑定表项，并且基于VLAN10使能了IPSPG功能。Host无法访问Internet（Host之间可以通信）。以Host_1为例说明。

- Host_1发往Internet的报文：当报文到达Router的IF1接口时，Router检查报文和绑定表匹配，允许报文通过。
- 从Internet发往Host_1的回程报文：当报文到达Router的IF3接口时，因为IF3接口在VLAN10内，Router会检查报文是否和绑定表匹配，因匹配失败（绑定表中无对应的绑定表项）而丢弃报文。

图 14-15 IPSPG 中未配置上行信任接口导致业务不通



步骤2 解决办法

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**dhcp enable**，全局使能DHCP功能。
3. 执行命令**dhcp snooping enable**，全局使能DHCP Snooping功能。
4. 执行命令**interface interface-type interface-number**，进入IF3接口视图。
5. 执行命令**dhcp snooping trusted**，配置IF3接口为信任状态。

----结束

14.8.4 上行接口使能 IPSG 导致业务不通

故障现象

接口上使能IPSG后所有主机访问不了外网，业务不通。

操作步骤

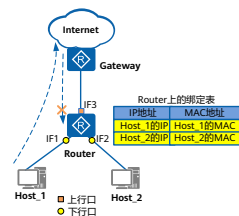
步骤1 检查使能IPSG的接口是否是上行口

正常情况下，IPSG使能在用户侧的接口（即下行口）。如果同时在上行口使能了IPSG，回程报文可能会被丢弃，导致用户业务不通。

如图14-16所示，在Router上创建了Host_1和Host_2的静态绑定表项，IF1、IF2和IF3上同时使能了IPSG功能后，Host无法访问Internet（Host之间可以互通）。以Host_1为例说明。

- Host_1发往Internet的报文：当报文到达Router的IF1接口时，Router检查报文和绑定表匹配，允许报文通过。
- 从Internet发往Host_1的回程报文：当报文到达Router的IF3接口时，因IF3使能了IPSG功能，Router检查报文是否和绑定表匹配，因匹配失败（绑定表中无对应的绑定表项）而丢弃报文。

图 14-16 上行接口使能 IPSG 导致业务不通



步骤2 解决办法

1. 执行命令**display ip source check user-bind interface interface-type interface-number**，查看上行口IF3是否使能了IPSG功能。
2. 如果显示“ip source check user-bind enable”表示接口使能了IPSG，请在接口视图下执行命令**undo ip source check user-bind enable**，去使能上行口IF3的IPSG功能。

----结束

14.8.5 配置 IP 和 MAC 绑定后，未绑定的主机仍可以上网

故障现象

配置IP和MAC绑定后，未绑定的主机仍可以上网。

操作步骤

步骤1 检查是否生成了静态绑定表

执行命令**display dhcp static user-bind { { interface interface-type interface-number | ip-address ip-address | mac-address mac-address | vlan vlan-id } * | all }**，查看静态绑定表信息。

如果没有静态绑定表项，可能IP和MAC的绑定方式不对。请检查是否是通过执行命令 **arp static ip-address mac-address** 进行的IP和MAC绑定，这是静态ARP而不是IPSPG，静态ARP无法实现未绑定的主机不能上网。

步骤2 创建静态绑定表

请执行命令 **user-bind static { { ip-address | ipv6-address } { start-ip [to end-ip] } &<1-10> | mac-address mac-address } * [interface interface-type interface-number] [vlan vlan-id [ce-vlan ce-vlan-id]]**，创建静态绑定表。

绑定表正确创建后，还需要在指定的接口或指定的VLAN下执行命令 **ip source check user-bind enable** 使能IPSPG，这样配置后可以实现未绑定的主机不能上网。

----结束

14.8.6 动态环境下未配置 DHCP Snooping 导致 IPSPG 功能不生效

故障现象

主机通过DHCP服务器可以动态获取到IP地址，使能IPSPG后功能不生效。

操作步骤

步骤1 检查DHCP Snooping绑定表是否存在。

在主机通过DHCP方式获取IP地址的环境下，IPSPG借助DHCP Snooping动态绑定表，对接口上接收的报文进行匹配检查。只有配置了DHCP Snooping功能，设备才会在主机上线时自动生成的DHCP Snooping绑定表。

步骤2 执行命令 **display dhcp snooping user-bind { { interface interface-type interface-number | ip-address ip-address | mac-address mac-address | vlan vlan-id } * | all }**，查看DHCP Snooping绑定表信息。

如果没有动态绑定表项，请参见[14.6.2 配置基于动态绑定表的IPSPG](#)中的步骤，完成DHCP Snooping的配置。主要过程如下：

1. 全局使能DHCP Snooping
2. 接口或VLAN下使能DHCP Snooping
3. 配置信任接口

DHCP Snooping配置完成后，主机重新上线后，设备会生成DHCP Snooping绑定表，IPSPG才能生效。并且，如果设备在没有生成DHCP Snooping动态绑定表的情况下使能了IPSPG，设备会拒绝所有除DHCP请求报文外的其他IP报文，DHCP主机的通信都会受到影响。所以，使能IPSPG功能之前请先配置DHCP Snooping生成动态绑定表。

----结束

14.9 IPSPG FAQ

提供IPSPG的常见问题集。例如：IPSPG是否支持批量绑定、IPSPG不生效有哪些原因等。

14.9.1 路由器是否支持一个接口绑定多个 IP 地址

路由器支持一个接口绑定多个IP地址：

- 如果这些IP地址不是连续的，可以重复输入1～10个地址。例如，将IP地址10.1.1.2、10.1.1.5和10.1.1.12绑定到接口Eth2/0/0。

```
<Huawei> system-view  
[Huawei] user-bind static ip-address 10.1.1.2 10.1.1.5 10.1.1.12 interface ethernet 2/0/0
```
- 如果这些IP地址是连续的，可以重复输入1～10个IP地址段。需要注意的是，IP地址段之间不能有交叉。例如，将10.2.1.1～10.2.1.10，10.2.1.20～10.2.1.30范围内的IP地址绑定到接口Eth2/0/0。

```
<Huawei> system-view  
[Huawei] user-bind static ip-address 10.2.1.1 to 10.2.1.10 10.2.1.20 to 10.2.1.30 interface ethernet 2/0/0
```

14.9.2 路由器是否支持一个 MAC 地址绑定多个 IP 地址

路由器支持一个MAC地址绑定多个IP地址：

- 如果这些IP地址不是连续的，可以重复输入1～10个地址。例如，将IP地址10.1.1.2、10.1.1.5和10.1.1.12绑定到MAC地址00e0-fc01-0101。

```
<Huawei> system-view  
[Huawei] user-bind static ip-address 10.1.1.2 10.1.1.5 10.1.1.12 mac-address 00e0-fc01-0101
```
- 如果这些IP地址是连续的，可以重复输入1～10个IP地址段。需要注意的是，IP地址段之间不能有交叉。例如，将10.2.1.1～10.2.1.10，10.2.1.20～10.2.1.30范围内的IP地址绑定到MAC地址00e0-fc01-0102。

```
<Huawei> system-view  
[Huawei] user-bind static ip-address 10.2.1.1 to 10.2.1.10 10.2.1.20 to 10.2.1.30 mac-address 00e0-fc01-0102
```

15 URPF 配置

配置URPF可以用来防止基于源地址欺骗的网络攻击行为。

15.1 URPF简介

介绍URPF的定义、由来和作用。

15.2 URPF原理描述

介绍URPF的实现原理。

15.3 URPF应用场景

介绍URPF的应用场景。

15.4 URPF配置注意事项

15.5 URPF缺省配置

介绍URPF缺省配置，实际应用的配置可以基于缺省配置进行修改。

15.6 配置URPF

介绍配置URPF具体命令和步骤。

15.7 URPF配置举例

通过示例介绍如何配置URPF。配置示例中包括组网需求、配置思路等。

15.1 URPF 简介

介绍URPF的定义、由来和作用。

定义

URPF（Unicast Reverse Path Forwarding）是单播逆向路径转发的简称，其主要功能是防止基于源IP地址欺骗的网络攻击行为。

目的

拒绝服务DoS（Denial of Service）攻击是一种阻止连接服务的网络攻击。DoS的攻击方式有很多种，最基本的DoS攻击就是利用合理的服务请求来占用过多的服务资源，从而使合法用户无法得到服务的响应。

URPF根据数据包的源IP地址在FIB表中查找对应的出接口，并判断该接口是否与数据包的来源接口相匹配。如果没有匹配表项则丢弃该数据包，从而预防IP欺骗，特别是对伪造IP源地址的DoS攻击非常有效。

受益

- 帮助网络维护者防御网络上的IP源攻击，降低对IP源攻击的维护成本。
- 用户能获得更安全、稳定的网络环境，不用担心因IP源攻击带来的困扰。

15.2 URPF 原理描述

介绍URPF的实现原理。

工作模式

在复杂的网络环境中应用URPF时，会遇到路由不对称的情况，即对端设备记录的路由路径不一样，此时使能URPF的设备可能丢弃合法报文，造成设备不能正确转发。

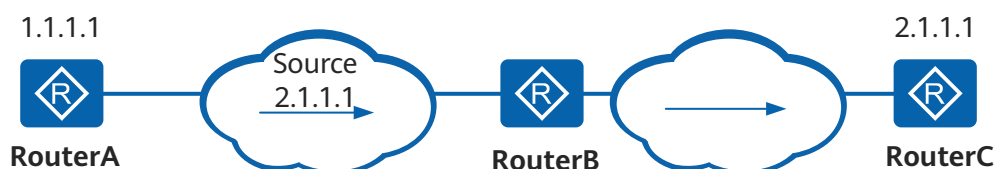
为了解决以上复杂网络中应用URPF的问题，设备实现了URPF的两种工作模式：

- 严格模式
严格模式下，设备不仅要求报文源地址在FIB表中存在相应表项，还要求接口匹配才能通过URPF检查。
建议在路由对称的环境下使用URPF严格模式，例如两个网络边界设备之间只有一条路径的话，这时，使用严格模式能够最大限度的保证网络的安全性。
- 松散模式
松散模式下，设备不检查接口是否匹配，只要FIB表中存在该报文源地址的路由，报文就可以通过。
建议在不能保证路由对称的环境下使用URPF的松散模式，例如两个网络边界设备之间如果有多条路径连接的话，路由的对称性就不能保证，在这种情况下，URPF的松散模式也可以保证较强的安全性。

工作原理

URPF通过获取报文的源地址和入接口，在FIB表中查找源地址对应的接口是否与入接口匹配。如果不匹配，则认为源地址是伪装的，丢弃该报文。通过这种工作方式，URPF能有效地防范网络中通过修改源地址而进行的恶意攻击行为。

图 15-1 URPF 原理



如图15-1所示，在RouterA上伪造源地址为2.1.1.1的报文向RouterB发起请求，RouterB响应请求时将向真正的“2.1.1.1”即RouterC发送报文。这种非法报文对RouterB和RouterC都造成了攻击。

如果在RouterB上启用URPF严格检查，则RouterB在收到源地址为2.1.1.1的报文时，URPF检查到以此报文源地址对应的接口与收到该报文的接口不匹配，报文会被丢弃。

15.3 URPF 应用场景

介绍URPF的应用场景。

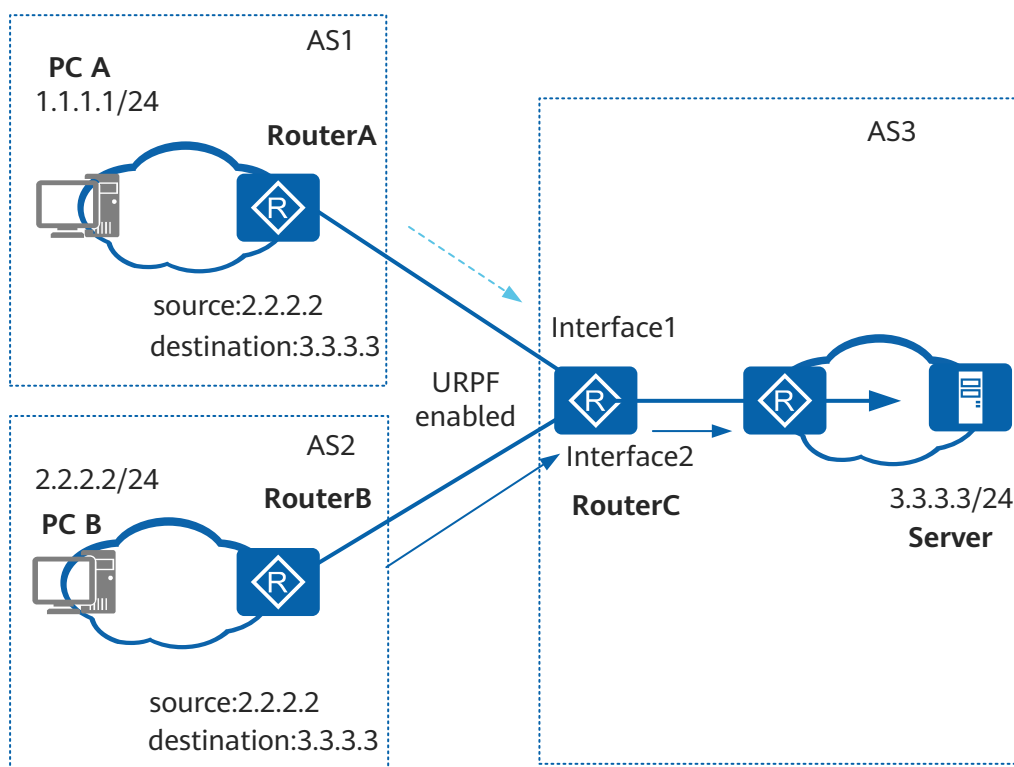
严格模式下的 URPF 应用

如图15-2所示，AS1和AS2与AS3之间为单连接。在RouterC的Interface1接口和Interface2接口上配置URPF，可以保护AS3免受来自AS1和AS2的源地址欺骗攻击。

如果AS1中的主机PC A伪造了一个源地址为2.2.2.2的报文，向AS3中的Server发送请求。RouterC在接收到这个报文后，检查其入接口是否匹配，发现源地址为2.2.2.2的报文应该从Interface2进入，则RouterC认为该报文源地址是伪造的，直接丢弃该报文。

从AS2发向Server的正常报文，检查通过后，被正常的转发。

图 15-2 URPF 单宿主客户应用环境示意图

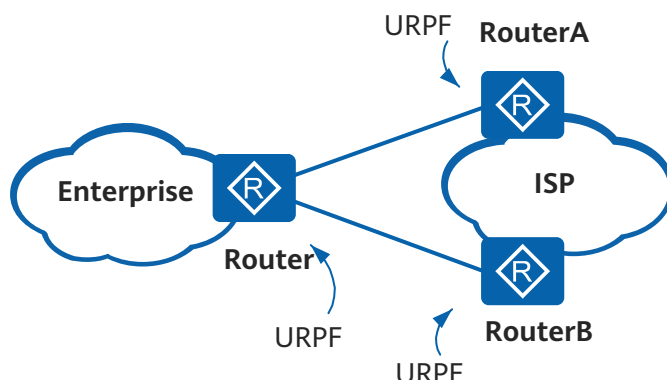


松散模式下的 URPF 应用

两个网络边界设备之间多个连接有单宿主单ISP客户和多宿主多ISP客户两种情况。

- 单宿主单ISP客户

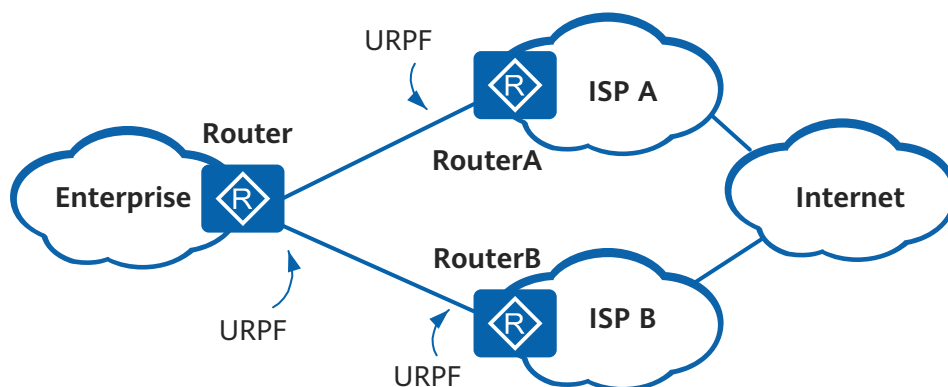
图 15-3 URPF 单宿主单 ISP 客户应用环境示意图



如图15-3所示，为了保证可靠性，某公司网络和某个ISP之间有两条连接。这时就不能够保证Enterprise和ISP之间路由的对称性，必须使用URPF松散模式。

- 多宿主多ISP客户

图 15-4 URPF 多宿主多 ISP 客户应用环境示意图



在图15-4所示环境中，客户与多个ISP连接，很难保证Enterprise和两个ISP之间路由的对称性，必须使用URPF松散模式。

客户与多个ISP连接下的URPF可以具有以下应用：

- 如果用户希望某些特殊报文任何情况都可以通过URPF的检查，可以在利用ACL指定这些特殊的源地地址允许通过。
- 许多用户连接的设备可能只有一条缺省路由指向ISP，此时，需要配置允许匹配缺省路由选项。

15.4 URPF 配置注意事项

介绍URPF的配置注意事项。

涉及网元

无需其他网元配合。

License 支持

URPF是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

15.5 URPF 缺省配置

介绍URPF缺省配置，实际应用的配置可以基于缺省配置进行修改。

URPF的缺省配置如表15-1所示。

表 15-1 URPF 缺省配置

参数	缺省值
URPF检查功能	未使能

15.6 配置 URPF

介绍配置URPF具体命令和步骤。

前置任务

在配置URPF之前，需完成以下任务：

- 配置接口的链路层协议参数，使接口的链路协议状态为Up。

15.6.1 配置接口的 URPF 检查模式

背景信息

在复杂的网络环境中应用URPF时，会遇到路由不对称的情况，即对端设备记录的路由路径不一样，此时使能URPF的设备可能丢弃合法报文，造成设备不能正确转发。

为了解决以上复杂网络中应用URPF的问题，设备实现了URPF的两种工作模式：

- 严格模式
严格模式下，设备不仅要求报文源地址在FIB（Forwarding Information Base）表中存在相应表项，还要求接口匹配才能通过URPF检查。
建议在路由对称的环境下使用URPF严格模式，例如两个网络边界设备之间只有一条路径的话，这时，使用严格模式能够最大限度的保证网络的安全性。

- 松散模式

松散模式下，设备不检查接口是否匹配，只要FIB表中存在该报文源地址的路由，报文就可以通过。

建议在不能保证路由对称的环境下使用URPF的松散模式，例如两个网络边界设备之间如果有多条路径连接的话，路由的对称性就不能保证，在这种情况下，URPF的松散模式也可以保证较强的安全性。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface interface-type interface-number**，进入接口视图。

步骤3 配置对接口的报文进行URPF检查。

- 配置对接口的IPv4报文进行URPF检查的模式。

执行命令**urpf { loose | strict } [allow-default-route] [acl acl-number]**，配置对接口的IPv4报文进行URPF检查的模式。

- 配置对接口的IPv6报文进行URPF检查的模式。

执行命令**ipv6 urpf { loose | strict } [allow-default-route] [acl acl-number]**，配置对接口的IPv6报文进行URPF检查的模式。

说明

如果需要配置对接口的IPv6报文进行URPF检查的功能，需要先使能接口的IPv6功能。请先在系统视图下执行命令**ipv6**，然后在接口视图下执行命令**ipv6 enable**。

----结束

15.6.2 检查 URPF 配置结果

操作步骤

步骤1 在接口视图下使用命令**display this**查看当前接口下是否配置了URPF功能。

----结束

15.7 URPF 配置举例

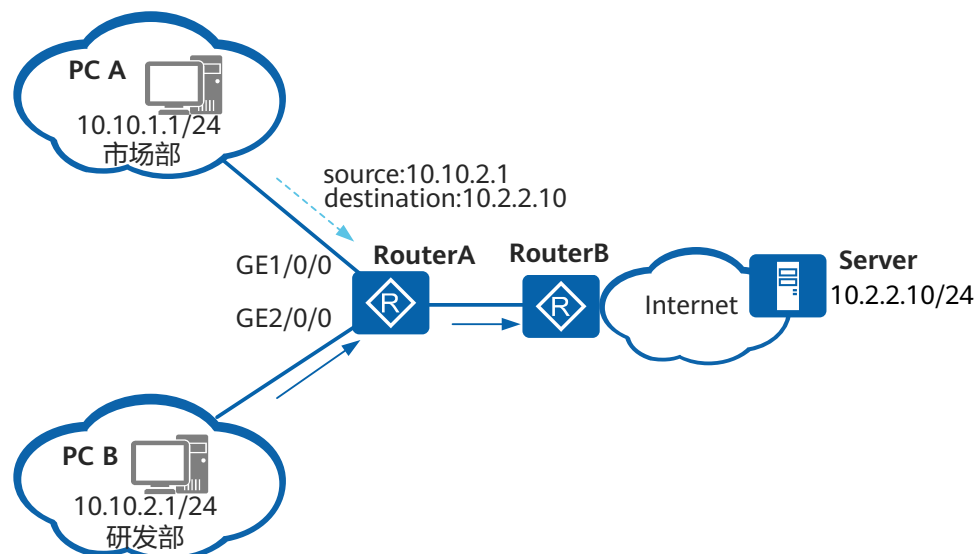
通过示例介绍如何配置URPF。配置示例中包括组网需求、配置思路等。

15.7.1 配置 URPF 功能示例

组网需求

如图15-5所示，某企业研发部和市场部通过接口GE2/0/0和接口GE1/0/0与RouterA连接，RouterA与外部的某个Server之间路由可达，研发部员工和市场部员工都可以通过RouterA访问该Server。公司希望在RouterA上进行配置，防止不同部门的员工利用源IP地址欺骗的方法超越权限，非法获取Server的服务。

图 15-5 配置 URPF 组网图



配置思路

该组网的配置思路如下：

在接口GE1/0/0和接口GE2/0/0配置URPF功能，并允许对缺省路由进行特殊处理。

操作步骤

步骤1 配置接口的URPF检查模式

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] interface gigabitethernet 1/0/0
[RouterA-GigabitEthernet1/0/0] urpf strict allow-default-route
[RouterA-GigabitEthernet1/0/0] ip address 10.10.1.5 24
[RouterA-GigabitEthernet1/0/0] quit
[RouterA] interface gigabitethernet 2/0/0
[RouterA-GigabitEthernet2/0/0] ip address 10.10.2.5 24
[RouterA-GigabitEthernet2/0/0] urpf strict allow-default-route
```

步骤2 验证配置结果

在GE1/0/0接口视图下执行命令**display this**查看URPF配置。

```
[RouterA-gigabitethernet1/0/0] display this
#
interface GigabitEthernet1/0/0
 ip address 10.10.1.5 255.255.255.0
 urpf strict allow-default-route
#
return
```

在GE2/0/0接口视图下执行命令**display this**查看URPF配置。

```
[RouterA-gigabitethernet2/0/0] display this
#
interface GigabitEthernet2/0/0
 ip address 10.10.2.5 255.255.255.0
```

```
urpf strict allow-default-route
#
return
```

----结束

配置文件

RouterA的配置文件

```
#
sysname RouterA
#
interface GigabitEthernet1/0/0
ip address 10.10.1.5 255.255.255.0
urpf strict allow-default-route
#
interface GigabitEthernet2/0/0
ip address 10.10.2.5 255.255.255.0
urpf strict allow-default-route
#
return
```

16 PKI 配置

- [16.1 PKI简介](#)
- [16.2 PKI原理描述](#)
- [16.3 PKI应用场景](#)
- [16.4 PKI配置注意事项](#)
- [16.5 PKI缺省配置](#)
- [16.6 PKI配置任务概览](#)
- [16.7 配置PKI](#)
- [16.8 维护PKI](#)
- [16.9 PKI配置举例](#)
- [16.10 PKI常见配置错误](#)
- [16.11 PKI FAQ](#)

16.1 PKI 简介

定义

公钥基础设施PKI（Public Key Infrastructure），是一种遵循既定标准的证书管理平台，它利用公钥技术能够为所有网络应用提供安全服务。PKI技术是信息安全技术的核心，也是电子商务的关键和基础技术。

目的

随着网络技术和信息技术的发展，电子商务已逐步被人们所接受，并得到不断普及。但通过网络进行电子商务交易时，存在如下问题：

- 交易双方并不现场交易，无法确认双方的合法身份。
- 通过网络传输时信息易被窃取和篡改，无法保证信息的安全性。
- 交易双方发生纠纷时没有凭证可依，无法提供仲裁。

为了解决上述问题，PKI技术应运而生，其利用公钥技术保证在交易过程中能够实现身份认证、保密、数据完整性和不可否认性。因而在网络通信和网络交易中，特别是电子政务和电子商务业务，PKI技术得到了广泛的应用。

受益

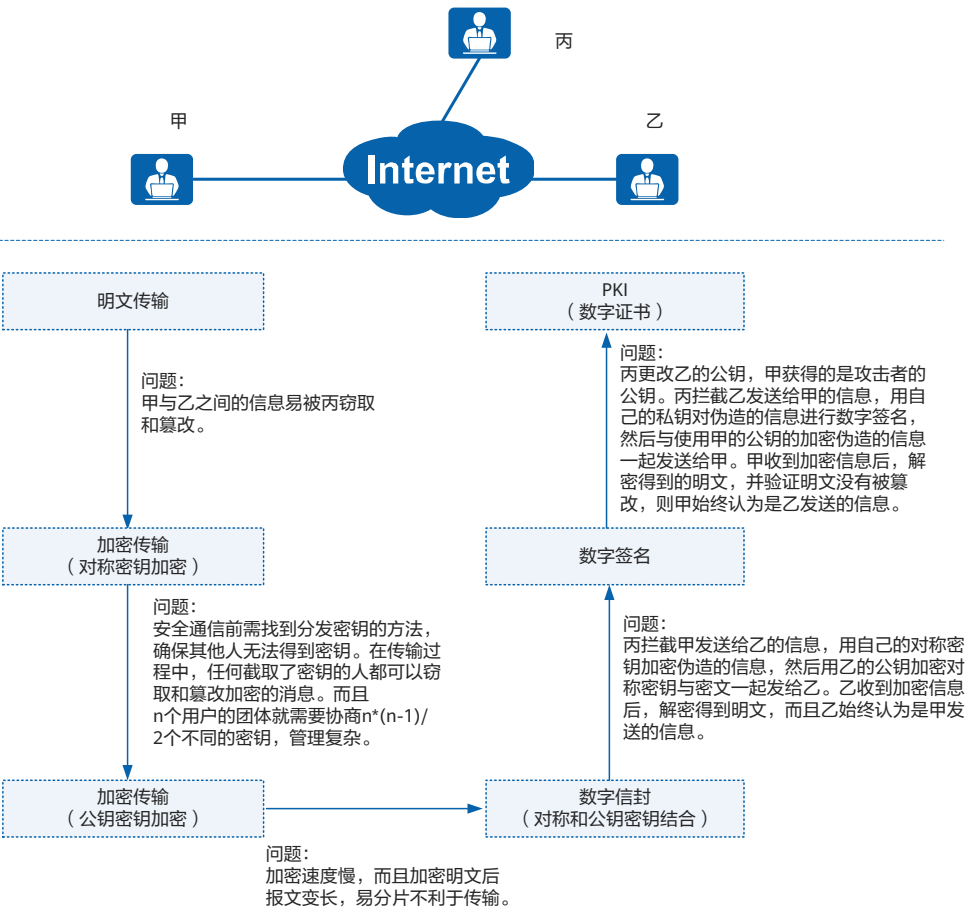
- 用户受益
 - 通过PKI证书认证技术，用户可以验证接入设备的合法性，从而可以保证用户接入安全、合法的网路中。
 - 通过PKI加密技术，可以保证网路中传输的数据的私密性，数据不会被篡改和窥探。
 - 通过PKI签名技术，可以保证数据的安全性，未授权的设备和用户无法查看该数据。
- 企业受益
 - 企业可以防止非法用户接入企业网路中。
 - 企业分支之间可以建立安全通道，保证企业数据的安全性。

16.2 PKI 原理描述

16.2.1 PKI 基本概念

PKI的核心技术就围绕着数字证书的申请、颁发和使用等整个生命周期进行展开，而在这整个生命周期过程中，PKI会使用到对称密钥加密、公钥加密、数字信封和数字签名技术。下面以图16-1为例介绍这些技术间的演进过程。甲和乙通过Internet进行通信，丙为攻击者专门破坏甲和乙间的通信。

图 16-1 演进示意图



对于这些概念的详细介绍请参见相应的章节。

16.2.1.1 加密

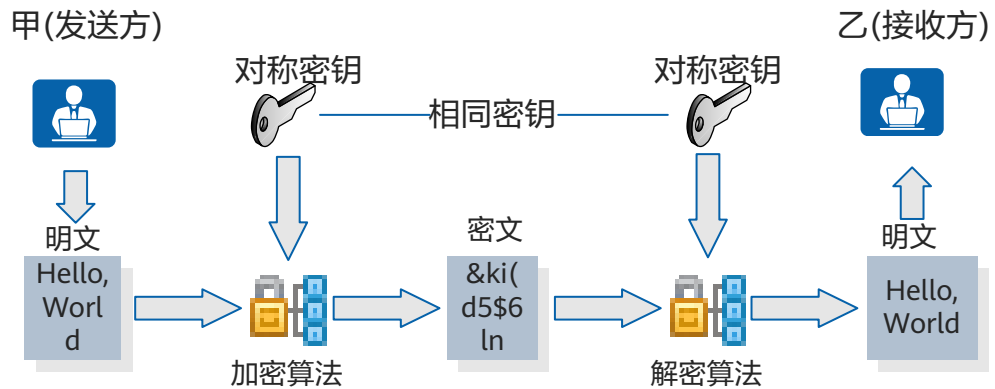
加密是通过网络传输信息的基础。通俗地讲，加密就是利用数学方法将明文(需要被隐蔽的数据)转换为密文（不可读的数据）从而达到保护数据的目的。

对称密钥加密

对称密钥加密又称为共享密钥加密，它使用同一个密钥对数据进行加密和解密。

对称密钥的加解密过程如图16-2所示。

图 16-2 对称密钥加解密过程示意图



甲与乙事先协商好对称密钥，具体加解密过程如下：

1. 甲使用对称密钥对明文加密，并将密文发送给乙。
2. 乙接收到密文后，使用对称密钥对密文解密，得到最初的明文。

对称密钥加密的优点是效率高，算法简单，系统开销小，适合加密大量数据。缺点是实现困难，扩展性差。实现困难原因在于进行安全通信前需要以安全方式进行密钥交换；扩展性差表现在每对通信用户之间都需要协商密钥， n 个用户的团体就需要协商 $n*(n-1)/2$ 个不同的密钥。

目前比较常用的对称密钥加密算法，主要包含DES（Data Encryption Standard）、3DES(Triple Data Encryption Standard)、AES（Advance Encrypt Standard）算法。其中，DES和3DES算法安全性低，存在安全风险，不推荐使用。

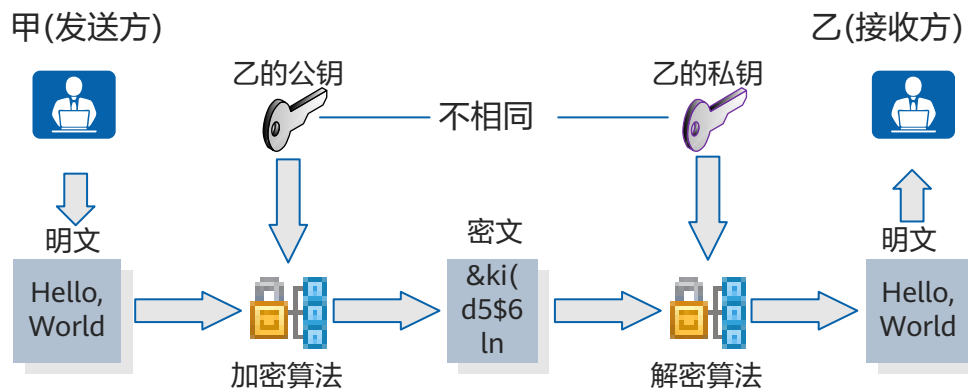
公钥加密

公钥加密又称为非对称密钥加密，它使用了两个不同的密钥：一个可对外界公开，称为“公钥”；一个只有所有者知道，称为“私钥”。

公钥加密解决了对称密钥的发布和管理问题，一个用于加密信息，另一个则用于解密信息，通信双方无需事先交换密钥就可进行保密通信。通常以公钥作为加密密钥，以私钥作为解密密钥。因为其他人没有对应的私钥，发送的加密信息仅该用户可以解读，从而实现通信的加密传输。

公钥加解密的过程如图16-3所示。

图 16-3 公钥加解密过程示意图



甲事先获得乙的公钥，具体加解密过程如下：

- 1. 甲使用乙的公钥对明文加密，并将密文发送给乙。
- 2. 乙收到密文后，使用自己的私钥对密文解密，得到最初的明文。

公钥加密的优点是无法从一个密钥推导出另一个密钥；公钥加密的信息只能用私钥进行解密。缺点是算法非常复杂，导致加密大量数据所用的时间较长，而且加密后的报文较长，不利于网络传输。

基于公钥加密的优缺点，公钥加密适合对密钥或身份信息敏感信息加密，从而在安全性上满足用户的需求。

目前比较常用的公钥加密算法，主要包含DH（Diffie-Hellman）、RSA（Ron Rivest、Adi Shamir、Leonard Adleman）和DSA（Digital Signature Algorithm）算法。

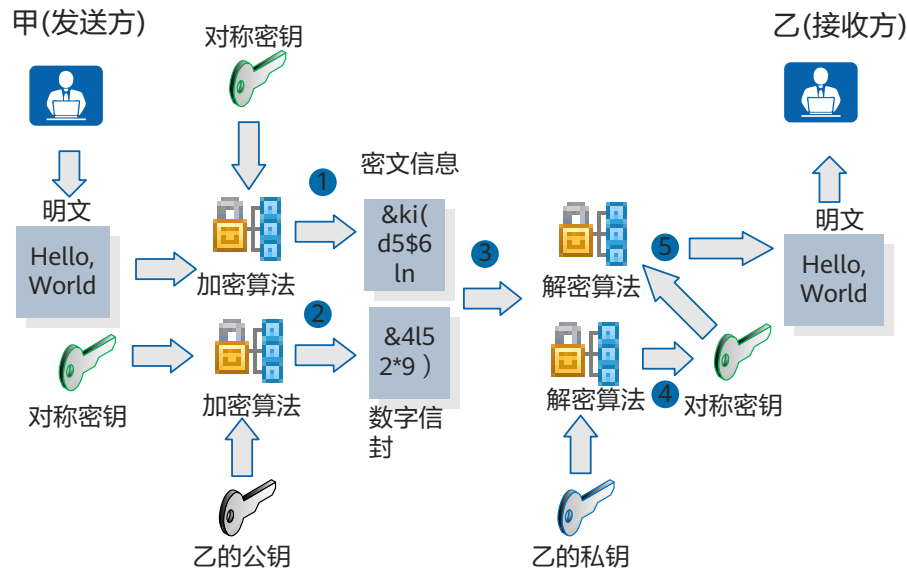
16.2.1.2 数字信封和数字签名

数字信封

数字信封是指发送方采用接收方的公钥来加密对称密钥后所得的数据。采用数字信封时，接收方需要使用自己的私钥才能打开数字信封得到对称密钥。

数字信封的加解密过程如图16-4所示。

图 16-4 数字信封的加解密过程示意图



甲事先获得乙的公钥，具体加解密过程如下：

- 1. 甲使用对称密钥对明文进行加密，生成密文信息。
- 2. 甲使用乙的公钥加密对称密钥，生成数字信封。
- 3. 甲将数字信封和密文信息一起发送给乙。
- 4. 乙接收到甲的加密信息后，使用自己的私钥打开数字信封，得到对称密钥。

5. 乙使用对称密钥对密文信息进行解密，得到最初的明文。

从加解密过程中，可以看出，数字信封技术结合了对称密钥加密和公钥加密的优点，解决了对称密钥的发布和公钥加密速度慢等问题，提高了安全性、扩展性和效率等。

但是，数字信封技术还有个问题，如果攻击者拦截甲的信息，用自己的对称密钥加密伪造的信息，并用乙的公钥加密自己的对称密钥，然后发送给乙。乙收到加密信息后，解密得到的明文，而且乙始终认为是甲发送的信息。此时，需要一种方法确保接收方收到的信息就是指定的发送方发送的。

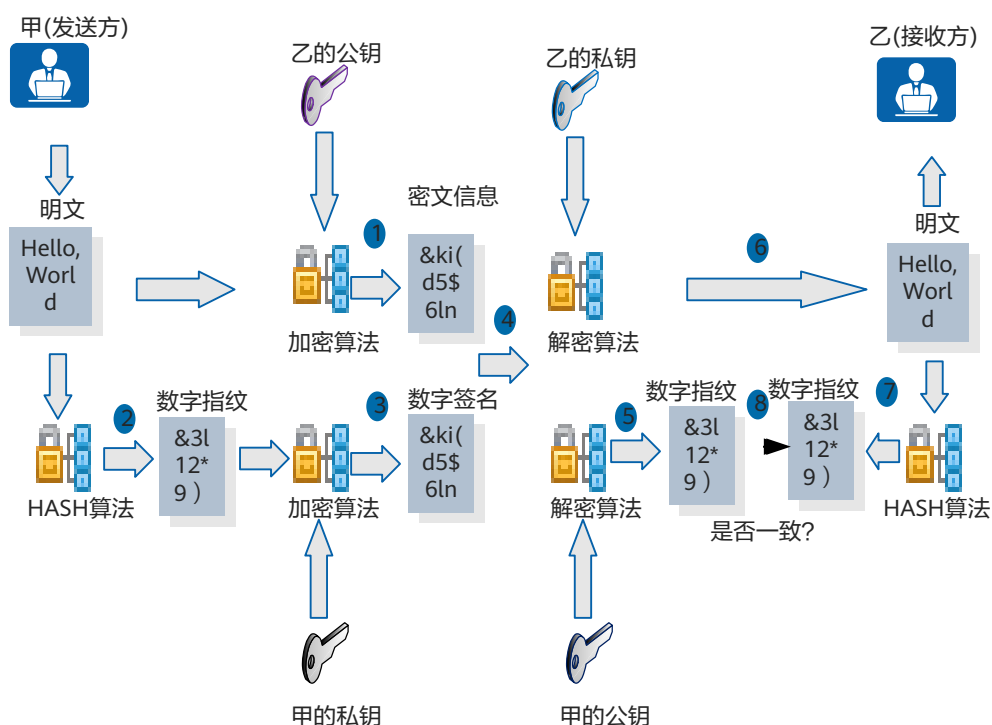
数字签名

数字签名是指发送方用自己的私钥对数字指纹进行加密后所得的数据。采用数字签名时，接收方需要使用发送方的公钥才能解开数字签名得到数字指纹。

数字指纹又称为信息摘要，它是指发送方通过HASH算法对明文信息计算后得出的数据。采用数字指纹时，发送方会将数字指纹和明文一起发送给接收方，接收方用同样的HASH算法对明文计算生成的数据指纹，与收到的数字指纹进行匹配，如果一致，便可确定明文信息没有被篡改。

数字签名的加解密过程如图16-5所示。

图 16-5 数字签名的加解密过程示意图



甲事先获得乙的公钥，具体加解密过程如下：

1. 甲使用乙的公钥对明文进行加密，生成密文信息。
2. 甲使用HASH算法对明文进行HASH运算，生成数字指纹。

3. 甲使用自己的私钥对数字指纹进行加密，生成数字签名。
4. 甲将密文信息和数字签名一起发送给乙。
5. 乙使用甲的公钥对数字签名进行解密，得到数字指纹。
6. 乙接收到甲的加密信息后，使用自己的私钥对密文信息进行解密，得到最初的明文。
7. 乙使用HASH算法对明文进行HASH运算，生成数字指纹。
8. 乙将生成的数字指纹与得到的数字指纹进行比较，如果一致，乙接受明文；如果不一致，乙丢弃明文。

从加解密过程中，可以看出，数字签名技术不但证明了信息未被篡改，还证明了发送方的身份。数字签名和数字信封技术也可以组合使用。

但是，数字签名技术还有个问题，如果攻击者更改乙的公钥，甲获得的是攻击者的公钥，攻击者拦截乙发送给甲的信息，用自己的私钥对伪造的信息进行数字签名，然后与使用甲的公钥的加密伪造的信息一起发送给甲。甲收到加密信息后，解密得到的明文，并验证明文没有被篡改，则甲始终认为是乙发送的信息。此时，需要一种方法确保一个特定的公钥属于一个特定的拥有者。

16.2.1.3 数字证书

数字证书简称证书，它是一个经证书授权中心（即在PKI中的[证书认证机构CA](#)）数字签名的文件，包含拥有者的公钥及相关身份信息。

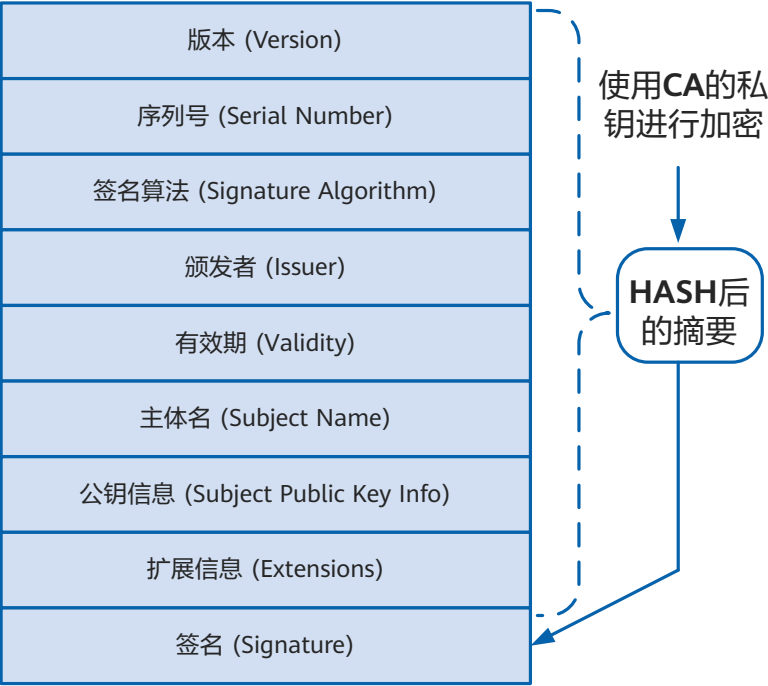
数字证书可以说是Internet上的安全护照或身份证。当人们到其他国家旅行时，用护照可以证实其身份，并被获准进入这个国家。数字证书提供的是网络上的身份证明。

数字证书技术解决了数字签名技术中无法确定公钥是指定拥有者的问题。

证书结构

最简单的证书包含一个公钥、名称以及证书授权中心的数字签名。一般情况下证书中还包括密钥的有效期，颁发者（证书授权中心）的名称，该证书的序列号等信息，证书的结构遵循X.509 v3版本的规范。[图16-6](#)展示了一个常见的证书结构。

图 16-6 证书结构示意图



证书的各字段解释：

- 版本：即使用X.509的版本，目前普遍使用的是v3版本（0x2）。
- 序列号：颁发者分配给证书的一个正整数，同一颁发者颁发的证书序列号各不相同，可用与颁发者名称一起作为证书唯一标识。
- 签名算法：颁发者颁发证书使用的签名算法。
- 颁发者：颁发该证书的设备名称，必须与颁发者证书中的主体名一致。通常为CA服务器的名称。
- 有效期：包含有效的起、止日期，不在有效期范围的证书为无效证书。
- 主体名：证书拥有者的名称，如果与颁发者相同则说明该证书是一个自签名证书。
- 公钥信息：用户对外公开的公钥以及公钥算法信息。
- 扩展信息：通常包含了证书的用法、CRL的发布地址等可选字段。
- 签名：颁发者用私钥对证书信息的签名。

证书分类

证书有四种类型，如表16-1所示。

表 16-1 证书类型

类型	描述	说明
自签名证书	自签名证书又称为根证书，是自己颁发给自己的证书，即证书中的颁发者和主体名相同。	申请者无法向CA申请本地证书时，可以通过设备生成自签名证书，可以实现简单证书颁发功能。 设备不支持对其生成的自签名证书进行生命周期管理（如证书更新、证书撤销等），为了确保设备和证书的安全，建议用户替换为自己的本地证书。
CA证书	CA自身的证书。如果PKI系统中没有多层级CA，CA证书就是自签名证书；如果有多层级CA，则会形成一个CA层次结构，最上层的CA是根CA，它拥有一个CA“自签名”的证书。	申请者通过验证CA的数字签名从而信任CA，任何申请者都可以得到CA的证书（含公钥），用以验证它所颁发的本地证书。
本地证书	CA颁发给申请者的证书。	-
设备本地证书	设备根据CA证书给自己颁发的证书，证书中的颁发者名称是CA服务器的名称。	申请者无法向CA申请本地证书时，可以通过设备生成设备本地证书，可以实现简单证书颁发功能。

证书格式

设备支持三种文件格式保存证书，如表16-2所示。

表 16-2 证书格式

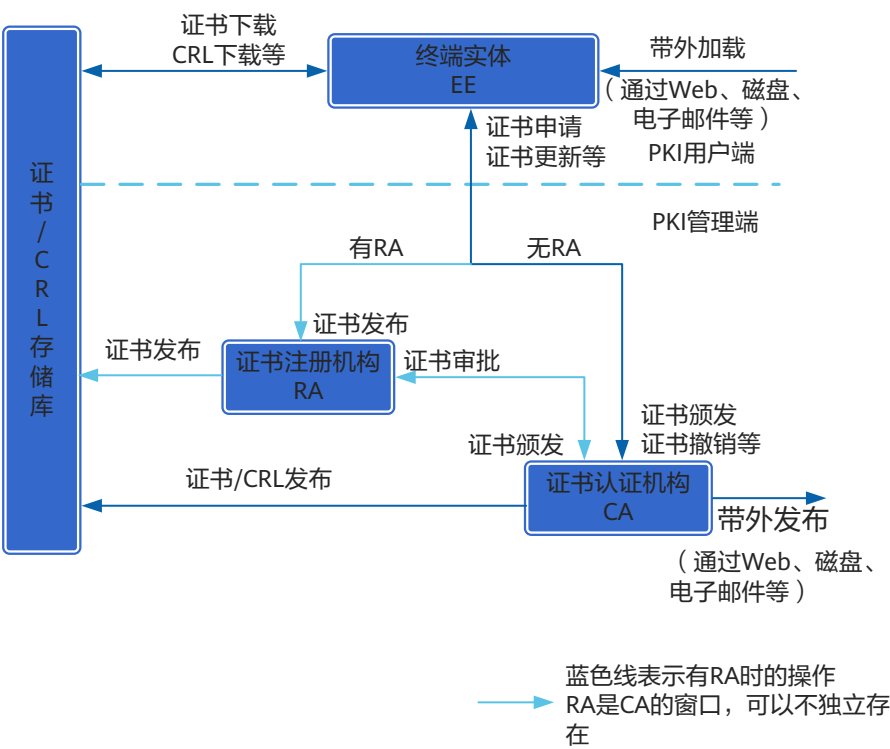
格式	描述	说明
PKCS#12	以二进制格式保存证书，可以包含私钥，也可以不包含私钥。常用的后缀有：.P12和.PFX。	对于证书后缀为.CER或.CRT，可以用记事本打开证书，查看证书内容来区分证书格式。 - 如果有类似 " -----BEGIN CERTIFICATE----- " 和 " -----END CERTIFICATE----- " 的头尾标记，则证书格式为PEM。 - 如果是乱码，则证书格式为DER。
DER	以二进制格式保存证书，不包含私钥。常用的后缀有：.DER、.CER和.CRT。	

格式	描述	说明
PEM	以ASCII码格式保存证书，可以包含私钥，也可以不包含私钥。常用的后缀有：.PEM、.CER和.CRT。	

16.2.2 PKI 体系架构

如图16-7所示，一个PKI体系由终端实体、证书认证机构、证书注册机构和证书/CRL存储库四部分共同组成。

图 16-7 PKI 体系架构



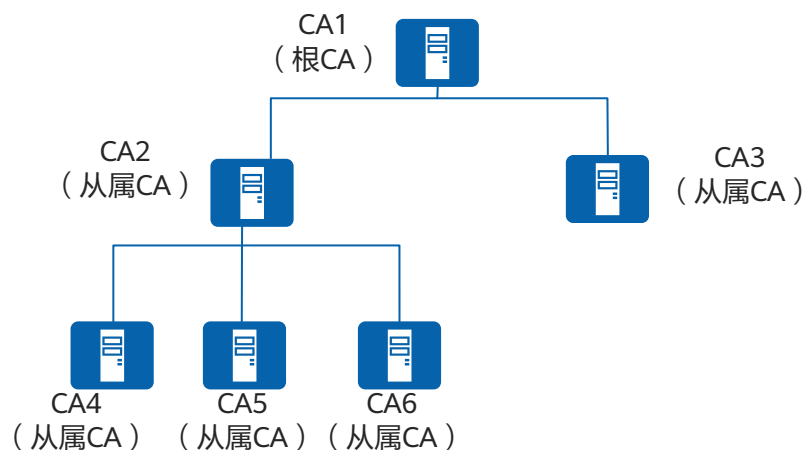
- 终端实体EE（End Entity）
终端实体也称为PKI实体，它是PKI产品或服务的最终使用者，可以是个人、组织、设备（如路由器、防火墙）或计算机中运行的进程。
- 证书认证机构CA（Certificate Authority）
CA是PKI的信任基础，是一个用于颁发并管理数字证书的可信实体。它是一种权威性、可信性和公正性的第三方机构，通常由服务器充当，例如Windows Server 2008。

如图16-8所示，CA通常采用多层次的分级结构，根据证书颁发机构的层次，可以划分为根CA和从属CA。

- 根CA是公钥体系中第一个证书颁发机构，它是信任的起源。根CA可以为其它CA颁发证书，也可以为其它计算机、用户、服务颁发证书。对大多数基于证书的应用程序来说，使用证书的认证都可以通过证书链追溯到根CA。根CA通常持有一个自签名证书。
- 从属CA必须从上级CA处获取证书。上级CA可以是根CA或者是一个已由根CA授权可颁发从属CA证书的从属CA。上级CA负责签发和管理下级CA的证书，最下一级的CA直接面向用户。例如，CA2和CA3是从属CA，持有CA1发行的CA证书；CA4、CA5和CA6是从属CA，持有CA2发行的CA证书。

当某个PKI实体信任一个CA，则可以通过证书链来传递信任，证书链就是从用户的证书到根证书所经过的一系列证书的集合。当通信的PKI实体收到待验证的证书时，会沿着证书链依次验证其颁发者的合法性。

图 16-8 CA 层次示意图



CA的核心功能就是发放和管理数字证书，包括：证书的颁发、证书的更新、证书的撤销、证书的查询、证书的归档、证书废除列表CRL（Certificate Revocation List）的发布等。

- 证书注册机构RA（Registration Authority）

RA是数字证书注册审批机构，RA是CA面对用户的窗口，是CA的证书发放、管理功能的延伸，它负责接受用户的证书注册和撤销申请，对用户的信息进行审核，并决定是否向CA提交签发或撤销数字证书的申请。

RA作为CA功能的一部分，实际应用中，通常RA并不一定独立存在，而是和CA合并在一起。RA也可以独立出来，分担CA的一部分功能，减轻CA的压力，增强CA系统的安全性。

- 证书/CRL存储库

由于用户名称的改变、私钥泄露或业务中止等原因，需要存在一种方法将现行的证书吊销，即撤销公钥及相关的PKI实体身份信息的绑定关系。在PKI中，所使用的这种方法为证书废除列表CRL。

任何一个证书被撤销以后，CA就要发布CRL来声明该证书是无效的，并列出所有被废除的证书的序列号。因此，CRL提供了一种检验证书有效性的方式。

证书/CRL存储库用于对证书和CRL等信息进行存储和管理，并提供查询功能。构建证书/CRL存储库可以采用LDAP（Lightweight Directory Access Protocol）服务

器、FTP（File Transfer Protocol）服务器、HTTP（Hypertext Transfer Protocol）服务器或者数据库等等。其中，LDAP规范简化了笨重的X.500目录访问协议，支持TCP/IP，已经在PKI体系中被广泛应用于证书信息发布、CRL信息发布、CA政策以及与信息发布相关的各个方面。如果证书规模不是太大，也可以选择架设HTTP、FTP等服务器来储存证书，并为用户提供下载服务。

PKI的核心技术就围绕着本地证书的申请、颁发、存储、下载、安装、验证、更新和撤销的整个生命周期进行展开。

证书申请

证书申请即证书注册，就是一个PKI实体向CA自我介绍并获取证书的过程。通常情况下PKI实体会生成一对公私钥，公钥和自己的身份信息（包含在证书注册请求消息中）被发送给CA用来生成本地证书，私钥PKI实体自己保存用来数字签名和解密对端实体发送过来的密文。

PKI实体向CA申请本地证书有以下两种方式：

- 在线申请
PKI实体支持通过SCEP（Simple Certificate Enrollment Protocol）或CMPv2（Certificate Management Protocol version 2）协议向CA发送证书注册请求消息来申请本地证书。
- 离线申请（PKCS#10方式）
离线申请是指PKI实体使用PKCS#10格式打印出本地的证书注册请求消息并保存到文件中，然后通过带外方式（如Web、磁盘、电子邮件等）将文件发送给CA进行证书申请。

还有种方式，PKI实体可以为自己颁发一个自签名证书或本地证书，实现简单的证书颁发功能。

证书颁发

PKI实体向CA申请本地证书时，如果有RA，则先由RA审核PKI实体的身份信息，审核通过后，RA将申请信息发送给CA。CA再根据PKI实体的公钥和身份信息生成本地证书，并将本地证书信息发送给RA。如果没有RA，则直接由CA审核PKI实体身份信息。

证书存储

CA生成本地证书后，CA/RA会将本地证书发布到证书/CRL存储库中，为用户提供下载服务和目录浏览服务。

证书下载

PKI实体通过SCEP或CMPv2协议向CA服务器下载已颁发的证书，或者通过LDAP、HTTP或者带外方式，下载已颁发的证书。该证书可以是自己的本地证书，也可以是CA/RA证书或者其他PKI实体的本地证书。

证书安装

PKI实体下载证书后，还需安装证书，即将证书导入到设备的内存中，否则证书不生效。该证书可以是自己的本地证书，也可以是CA/RA证书，或其他PKI实体的本地证书。

证书验证

PKI实体获取对端实体的证书后，当需要使用对端实体的证书时，例如与对端建立安全隧道或安全连接，通常需要验证对端实体的本地证书和CA的合法性（证书是否有效或者是否属于同一个CA颁发等）。如果证书颁发者的证书无效，则由该CA颁发的所有证书都不再有效。但在CA证书过期前，设备会自动更新CA证书，异常情况下才会出现CA证书过期现象。

PKI实体可以使用CRL或者OCSP（Online Certificate Status Protocol）方式检查证书是否有效。使用CRL方式时，PKI实体先查找本地内存的CRL，如果本地内存没有CRL，则需下载CRL并安装到本地内存中，如果证书在CRL中，表示此证书已被撤销。使用OCSP方式时，PKI实体向OCSP服务器发送一个对于证书状态信息的请求，OCSP服务器会回复一个“有效”（证书没有被撤销）、“过期”（证书已被撤销）或“未知”（OCSP服务器不能判断请求的证书状态）的响应。

证书更新

当证书过期、密钥泄露时，PKI实体必须更换证书，可以通过重新申请来达到更新的目的，也可以使用SCEP或CMPv2协议自动进行更新。

设备在证书即将过期前，先申请一个证书作为“影子证书”，在当前证书过期后，影子证书成为当前证书，完成证书更新功能。

申请“影子证书”的过程，实质上是一个新的证书注册的过程。

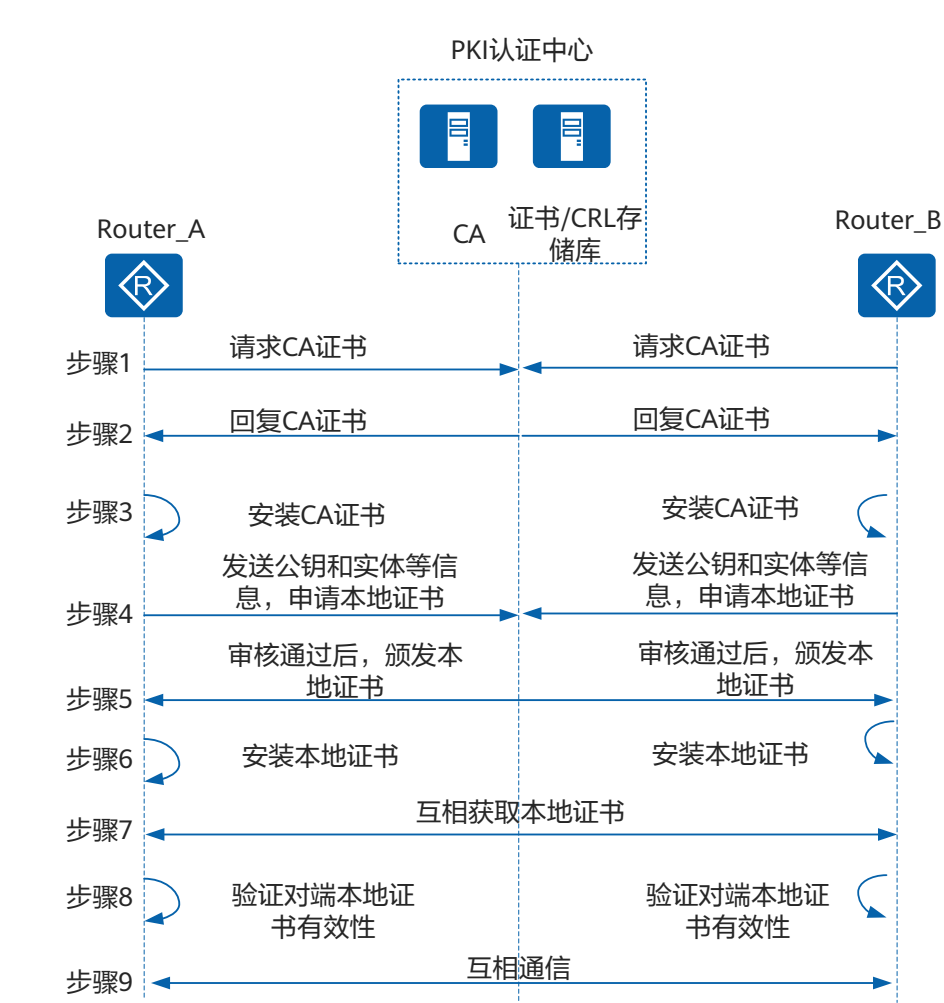
证书撤销

由于用户身份、用户信息或者用户公钥的改变、用户业务中止等原因，用户需要将自己的数字证书撤销，即撤销公钥与用户身份信息的绑定关系。在PKI中，CA主要采用CRL或OCSP协议撤销证书，而PKI实体撤销自己的证书是通过带外方式申请。

16.2.3 PKI 工作机制

针对一个使用PKI的网络，配置PKI的目的就是为指定的PKI实体向CA申请一个本地证书，并由设备对证书的有效性进行验证。PKI具体工作过程如图16-9所示。

图 16-9 PKI 工作过程示意图



1. PKI实体向CA请求CA证书，即CA服务器证书。
2. CA收到PKI实体的CA证书请求时，将自己的CA证书回复给PKI实体。
3. PKI实体收到CA证书后，安装CA证书。
当PKI实体通过SCEP协议申请本地证书时，PKI实体会用配置的HASH算法对CA证书进行运算得到数字指纹，与提前配置的CA服务器的数字指纹进行比较，如果一致，则PKI实体接受CA证书，否则PKI实体丢弃CA证书。
4. PKI实体向CA发送证书注册请求消息（包括配置的密钥对中的公钥和PKI实体信息）。
 - 当PKI实体通过SCEP协议申请本地证书时，PKI实体对证书注册请求消息使用CA证书的公钥进行加密和自己的私钥进行数字签名。如果CA要求验证挑战密码，则证书注册请求消息必须携带挑战密码（与CA的挑战密码一致）。
 - 当PKI实体通过CMPv2协议申请本地证书时，PKI实体可以使用额外证书（其他CA颁发的本地证书）或者消息认证码方式进行身份认证。
 - 额外证书方式

PKI实体对证书注册请求消息使用CA证书的公钥进行加密和PKI实体的额外证书相对应的私钥进行数字签名。

- 消息认证码方式

PKI实体对证书注册请求消息使用CA证书的公钥进行加密，而且证书注册请求消息必须包含消息认证码的参考值和秘密值（与CA的消息认证码的参考值和秘密值一致）。

5. CA收到PKI实体的证书注册请求消息。

- 当PKI实体通过SCEP协议申请本地证书时，CA使用自己的私钥和PKI实体的公钥解密数字签名并验证数字指纹。数字指纹一致时，CA才会审核PKI实体身份等信息，审核通过后，同意PKI实体的申请，颁发本地证书。然后CA使用PKI实体的公钥进行加密和自己的私钥进行数字签名，将证书发送给PKI实体，也会发送到证书/CRL存储库。

- 当PKI实体通过CMPv2协议申请本地证书时：

- 额外证书方式

CA使用自己的私钥解密和PKI实体的额外证书中的公钥解密数字签名并验证数字指纹。数字指纹一致时，CA才会审核PKI实体身份等信息，审核通过后，同意PKI实体的申请，颁发本地证书。然后CA使用PKI实体的额外证书中的公钥进行加密和自己的私钥进行数字签名，将证书发送给PKI实体，也会发送到证书/CRL存储库。

- 消息认证码方式

CA使用自己的私钥解密后，并验证消息认证码的参考值和秘密值。参考值和秘密值一致时，CA才会审核PKI实体身份等信息，审核通过后，同意PKI实体的申请，颁发本地证书。然后CA使用PKI实体的公钥进行加密，将证书发送给PKI实体，也会发送到证书/CRL存储库。

6. PKI实体收到CA发送的证书信息。

- 当PKI实体通过SCEP协议申请本地证书时，PKI实体使用自己的私钥解密，并使用CA的公钥解密数字签名并验证数字指纹。数字指纹一致时，PKI实体接受证书信息，然后安装本地证书。

- 当PKI实体通过CMPv2协议申请本地证书时：

- 额外证书方式

PKI实体使用额外证书相对应的私钥解密，并使用CA的公钥解密数字签名并验证数字指纹。数字指纹一致时，PKI实体接受证书信息，然后安装本地证书。

- 消息认证码方式

PKI实体使用自己的私钥解密，并验证消息认证码的参考值和秘密值。参考值和秘密值一致时，PKI实体接受证书信息，然后安装本地证书。

7. PKI实体间互相通信时，需各自获取并安装对端实体的本地证书。PKI实体可以通过HTTP/LDAP等方式下载对端的本地证书。
8. PKI实体安装对端实体的本地证书后，通过CRL或OCSP方式验证对端实体的本地证书的有效性。
9. 对端实体的本地证书有效时，PKI实体间才可以使用对端证书的公钥进行加密通信。

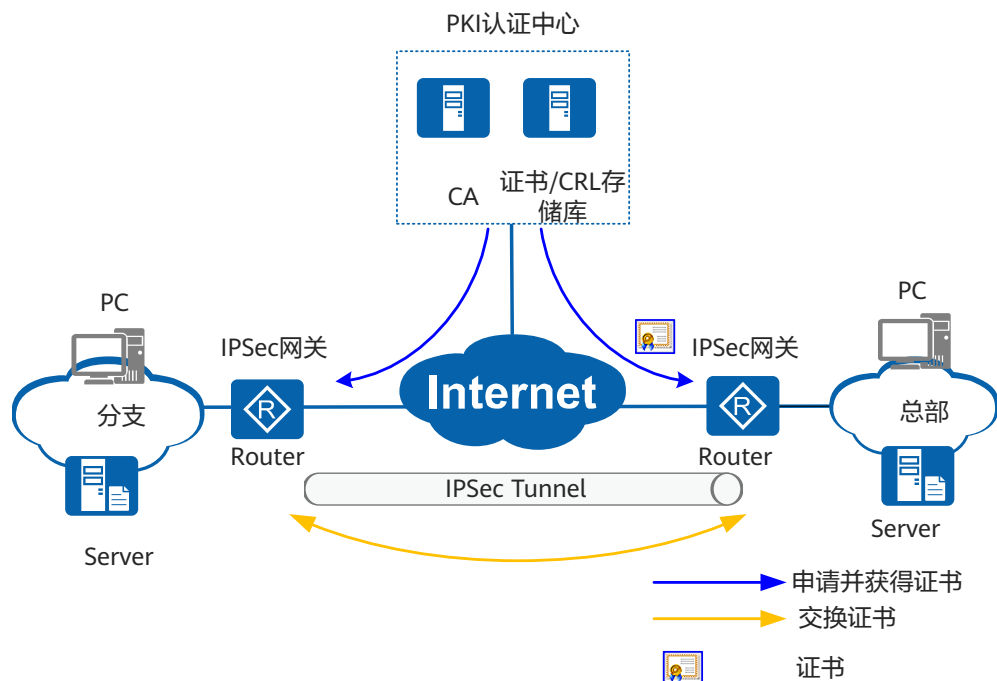
如果PKI认证中心有RA，则PKI实体也会下载RA证书。由RA审核PKI实体的本地证书申请，审核通过后将申请信息发送给CA来颁发本地证书。

16.3 PKI 应用场景

16.3.1 在 IPSec VPN 中应用

如图16-10所示，设备作为网络A和网络B的出口网关，网络A和网络B的内网用户通过公网进行相互通信。因为公网是不安全的网络，为了保护数据的安全性，设备采用IPSec技术，与对端设备建立IPSec隧道。通常情况下，IPSec采用预共享密钥方式协商IPSec。但是，在大型网络中IPSec采用预共享密钥方式时存在密钥交换不安全和配置工作量大的问题。为了解决上述问题，设备之间可以采用基于PKI的证书进行身份认证来完成IPSec隧道的建立。

图 16-10 在 IPSec VPN 中应用组网图



采用基于PKI的证书进行身份认证后，IPSec在进行IKE协商过程中交换密钥时，会对通信双方进行身份认证，保证了密钥交换的安全。而且，证书可以为IPSec提供集中的密钥管理机制，并增强整个IPSec网络的可扩展性。同时，在采用证书认证的IPSec网络中，每台设备都拥有PKI认证中心颁发的本地证书。有新设备加入时，只需要为新增加的设备申请一个证书，新设备就可以与其它设备进行安全通讯，而不需要对其他设备的配置进行修改，这大大减少了配置工作量。

16.4 PKI 配置注意事项

涉及网元

- PKI认证中心（包含CA服务器、证书/CRL存储服务器等）

- PKI实体

License 支持

PKI特性无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

16.5 PKI 缺省配置

表 16-3 PKI 的缺省配置

参数	缺省值
PKI实体	无
PKI域	default
RSA密钥对	default
SM2密钥对	无
设备保存证书请求、证书和CRL时的文件格式	PEM
证书状态检查方式	CRL方式

16.6 PKI 配置任务概览

PKI配置任务如[表16-4](#)所示。

表 16-4 PKI 配置任务概览

场景	描述	对应任务
在线申请本地证书	用户可以使用SCEP或CMPv2协议在线申请本地证书。使用SCEP或CMPv2协议都可以自动更新证书，SCEP比CMPv2协议维护更方便，但使用CMPv2协议可以为其他设备申请本地证书。	使用SCEP协议申请本地证书时，请按照如下顺序依次配置： 1. 16.7.1 申请本地证书的预配置 2. 16.7.2 申请和更新本地证书中的16.7.2.1 配置通过SCEP协议为PKI实体申请和更新本地证书 3. 16.7.5 验证CA证书和本地证书 使用CMPv2协议申请本地证书时，请按照如下顺序依次配置： 1. 16.7.1 申请本地证书的预配置 2. 16.7.2 申请和更新本地证书中的16.7.2.2 配置通过CMPv2协议为PKI实体申请和更新本地证书 3. 16.7.4（可选）安装本地证书 4. 16.7.5 验证CA证书和本地证书

场景	描述	对应任务
离线申请本地证书	如果受网络环境限制，设备无法访问CA服务器，可选择离线申请本地证书。 用户可以通过设备生成证书申请文件，然后通过带外方式（Web、磁盘、电子邮件等）将证书申请文件发送给CA申请本地证书;也可以无需通过设备生成证书申请文件，直接通过Web方式将申请证书信息发送给CA申请本地证书。	通过设备生成证书申请文件时，请按照如下顺序依次配置： 1. 16.7.1 申请本地证书的预配置 2. 16.7.2 申请和更新本地证书中的16.7.2.3 配置为PKI实体离线申请本地证书 3. 16.7.3（可选）下载本地证书 4. 16.7.4（可选）安装本地证书 5. 16.7.5 验证CA证书和本地证书 未通过设备生成证书申请文件时，请按照如下顺序依次配置： 1. 直接通过Web方式将申请证书信息发送给CA申请本地证书 2. 下载CA提供的CA证书、本地证书和密钥对并上传至设备的存储介质中 3. 安装密钥对，请参考16.7.1 申请本地证书的预配置中的16.7.1.2 配置RSA/SM2密钥对 4. 安装CA证书，请参考16.7.1 申请本地证书的预配置中的16.7.1.3.2（可选）配置为PKI实体安装CA证书 5. 安装本地证书，请参考16.7.4（可选）安装本地证书 6. 验证证书，请参考16.7.5 验证CA证书和本地证书

16.7 配置 PKI

16.7.1 申请本地证书的预配置

16.7.1.1 配置 PKI 实体信息

背景信息

本地证书是由CA进行数字签名并颁发的。它是公钥与PKI实体身份信息的绑定。PKI实体信息就是PKI实体的身份信息，CA根据PKI实体提供的身份信息来唯一标识证书申请者。因此，申请本地证书时，PKI实体必须将包含PKI实体信息的证书注册请求消息发送给CA。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki entity *entity-name***，创建PKI实体并进入PKI实体视图，或者直接进入PKI实体视图。

缺省情况下，系统未配置PKI实体。

说明

由于Windows Server 2003服务器处理能力有限，与该型号服务器对接时，设备上不能配置过多实体信息或携带密钥对位数过大的密钥对，否则可能导致设备与服务器对接失败。

步骤3 执行命令**common-name *common-name***，配置PKI实体的通用名称。

缺省情况下，系统未配置PKI实体的通用名称。

为了更好的标识证书申请者的唯一身份，还需配置以下可选步骤的参数，作为PKI实体的一种别名。否则，当PKI实体间的通用名称相同时，会导致某PKI实体申请证书失败。

步骤4 （可选）执行命令**ip-address [*unstructured-address*] { *ipv4-address* | *interface-type interface-number* }**，配置PKI实体的IP地址。

缺省情况下，系统未配置PKI实体的IP地址。

PKI实体申请本地证书时，如果配置了命令**enrollment-request specific**，则PKI实体可以配置**unstructured-name**参数。

步骤5 （可选）执行命令**fqdn [*unstructured-name*] *fqdn-name***，配置PKI实体的FQDN名称。

缺省情况下，系统未配置PKI实体的FQDN名称。

PKI实体申请本地证书时，如果配置了命令**enrollment-request specific**，则PKI实体可以配置**unstructured-name**参数。

步骤6 （可选）执行命令**email *email-address***，配置PKI实体的电子邮箱地址。

缺省情况下，系统未配置PKI实体的电子邮箱地址。

步骤7 （可选）执行命令**country *country-code***，配置PKI实体所属的国家代码。

缺省情况下，系统未配置PKI实体的国家代码。

步骤8 （可选）执行命令**locality *locality-name***，配置PKI实体所在的地理区域名称。

缺省情况下，系统未配置PKI实体的地理区域名称。

步骤9 （可选）执行命令**state state-name**，配置PKI实体所属的州或省。

缺省情况下，系统未配置PKI实体所属的州或者省。

步骤10 （可选）执行命令**organization organization-name**，配置PKI实体所属的组织名称。

缺省情况下，系统未配置PKI实体的组织名称。

步骤11 （可选）执行命令**organization-unit organization-unit-name**，配置PKI实体所属的部门名称。

缺省情况下，系统未配置PKI实体所在的部门名称。

步骤12 （可选）执行命令**serial-number**，将设备的序列号添加到PKI实体。

缺省情况下，系统未将设备的序列号添加到PKI实体。

----结束

16.7.1.2 配置 RSA/SM2 密钥对

背景信息

本地证书是由CA进行数字签名并颁发的。它是公钥与PKI实体身份信息的绑定。因此，申请本地证书时，需先配置RSA/SM2密钥对生成公钥和私钥。公钥由PKI实体发送给CA，可以被对端用来加密明文；私钥由PKI实体保留，可以被用来数字签名和解密对端发送过来的密文。

配置RSA/SM2密钥对有以下两种方式：

- 创建RSA/SM2密钥对
设备上可以直接创建密钥对，无需再导入密钥对到设备的内存中。
- 导入RSA/SM2密钥对
当需要使用其他PKI实体产生的密钥对时，可以通过FTP/SFTP传到设备上，然后导入密钥对到设备的内存中，否则密钥对不生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 请根据实际情况选择配置。

- 创建RSA/SM2密钥对
 - 执行命令**pki rsa local-key-pair create key-name [modulus modulus-size] [exportable]**，创建证书申请时使用的RSA密钥对。
 - 执行命令**pki sm2 local-key-pair create key-name [exportable]**，创建证书申请时使用的SM2密钥对。
- 导入RSA/SM2密钥对
 - 执行命令**pki import rsa-key-pair key-name [include-cert realm realm-name] { pem | pkcs12 } file-name [exportable] [password password]**或执行命令**pki import rsa-key-pair key-name der file-name [exportable]**，将RSA密钥对和证书导入设备的内存中。
 - 执行命令**pki import sm2-key-pair key-name { der file-name [exportable] | pem file-name [exportable] [password password] }**，将SM2密钥对导入设备的内存中。

说明

仅当配置`exportable`参数时，创建的RSA/SM2密钥对才可以被导出。

由于Windows Server 2003服务器处理能力有限，与该型号服务器对接时，设备上不能配置过多实体信息或携带密钥对位数过大的密钥对，否则可能导致设备与服务器对接失败。

----结束

后续处理

- 当需要备份RSA密钥对或者RSA密钥对给其他设备使用时，可以执行命令**`pki export rsa-key-pair key-name [ and-certificate certificate-name ] { pem file-name [ 3des | aes | des ] | pkcs12 file-name } password password`**，将RSA密钥对导出到设备的存储介质中，同时支持导出与其关联的证书。然后用户可以通过SFTP获取RSA密钥对。
- 当需要备份SM2密钥对或者SM2密钥对给其他设备使用时，可以执行命令**`pki export sm2-key-pair key-name { der file-name | pem file-name [ password password ] }`**，将SM2密钥对导出到设备的存储介质中。然后用户可以通过FTP/SFTP获取SM2密钥对。
- RSA密钥对泄露、损坏、不用或丢失时，可以执行命令**`pki rsa local-key-pair destroy key-name`**，销毁指定的RSA密钥对。
配置后，系统会销毁设备中对应名称的RSA密钥对，以及备设备中对应名称的RSA密钥对。
- SM2密钥对泄露、损坏、不用或丢失时，可以执行命令**`pki sm2 local-key-pair destroy key-name`**，销毁指定的SM2密钥对。
配置后，系统会销毁设备中对应名称的SM2密钥对，以及备设备中对应名称的SM2密钥对。
- 用户不知道证书所对应的RSA密钥对时，可以执行命令**`pki match-rsa-key certificate-filename file-name`**，查找证书所对应的RSA密钥对。
- 用户不知道证书所对应的SM2密钥对时，可以执行命令**`pki match-sm2-key certificate-filename file-name`**，查找证书所对应的SM2密钥对。

16.7.1.3 配置为 PKI 实体获取 CA 证书

背景信息

申请本地证书时，PKI实体会将证书注册请求消息发送给CA。为了提高传输过程中的安全性，PKI实体必须使用CA的公钥对证书注册请求消息进行加密保护。因此，PKI实体必须先获取到CA证书，并从CA证书中获取CA的公钥。

说明

设备出厂时已经在`default`域初始了CA和本地证书，可以执行命令**`display pki certificate ca realm default`**查看CA证书信息。

配置流程

PKI实体获取CA证书需要先下载CA证书，然后再安装CA证书。

16.7.1.3.1 配置为 PKI 实体下载 CA 证书

背景信息

下载CA证书有如下几种方式，请根据CA提供的服务方式选择。

- 通过SCEP协议从CA服务器下载CA证书，将CA证书下载到设备的存储介质中。
- 通过HTTP协议从Web服务器上下载CA证书，将CA证书下载到设备的存储介质中。
- 通过LDAP协议从存放证书的服务器上下载CA证书，将CA证书下载到设备的存储介质中。
- 通过CMPv2协议从CMPv2服务器下载CA证书，将CA证书下载到设备的存储介质中。
- 通过带外方式（Web、磁盘、电子邮件等）获得CA证书后，上传到设备的存储介质中。

如果通过CMPv2协议申请本地证书时，这里下载的CA证书为CA服务器的根证书。

操作步骤

- 通过SCEP协议下载CA证书。

通过SCEP协议下载CA证书的具体配置请参见[16.7.2.1 配置通过SCEP协议为PKI实体申请和更新本地证书](#)。

- 通过HTTP方式下载CA证书。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**pki http [esc] url-address save-name**，配置通过HTTP方式下载CA证书。

*url-address*必须包含完整的证书文件及扩展名，例如http://10.1.1.1:8080/cert.cer。如果设置为域名方式，必须保证该域名可以正常解析。

- 通过LDAP方式下载CA证书。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**pki ldap ip ip-address port port version version [attribute attr-value] [authentication ldap-dn ldap-password] save-name dn dn-value**，配置通过LDAP方式下载CA证书。

- 通过CMPv2协议下载CA证书。

通过CMPv2协议下载CA证书的具体配置请参见[16.7.2.2 配置通过CMPv2协议为PKI实体申请和更新本地证书](#)。

- 通过带外方式下载CA证书。

用户通过Web、磁盘、电子邮件等方式获得CA证书后，需要手工上传到设备的存储介质中。也可以选择通过管理PC下载证书后，使用SFTP或Web方式上传到设备的存储介质中。

----结束

16.7.1.3.2（可选）配置为 PKI 实体安装 CA 证书

背景信息

下载的CA证书只有导入到设备的内存中才可以正常生效，并且设备会将导入内存证书文件保存到缺省目录下的ca_config.ini文件中，在重启后可以自动加载文件中记录的证书文件。

说明

请确保CA证书文件不超过1M，避免安装失败。

配置通过SCEP协议申请本地证书时，设备会自动安装CA证书，无需手动安装CA证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki import-certificate { ca realm *realm-name* { der | pkcs12 | pem } [filename *filename*] [replace] [no-check-validate] [no-check-hash-alg] | realm *realm-name* pem terminal password *password* }**或执行命令**pki import-certificate ca realm *realm-name* pkcs12 filename *filename* [no-check-validate] [no-check-hash-alg] password *password***，将CA证书导入到设备的内存中。

步骤3 （可选）执行命令**pki set-certificate expire-prewarning *day***，配置内存中的CA证书的过期预告警时间。

缺省情况下，内存中的CA证书的过期预告警时间为90天。

----结束

后续处理

- 如果需要把CA证书拷贝到其他设备上使用，可以执行命令**pki export-certificate ca realm *realm-name* { der | pem | pkcs12 }**，将CA证书导出到设备存储介质中。然后，用户可以通过FTP/SFTP取出CA证书。
- 如果需要把系统缺省内置的CA证书拷贝到其他设备上使用，可以执行命令**pki export-certificate default ca filename *filename***，将系统缺省内置的CA证书导出到设备存储介质中。然后，用户可以通过FTP/SFTP取出CA证书。
- 如果CA证书过期或者不用，可以执行命令**pki delete-certificate ca realm *realm-name***，从内存中删除CA证书。

16.7.1.4 检查申请本地证书的预配置的配置结果

前提条件

已经完成配置PKI实体信息、RSA密钥对或者CA证书。

操作步骤

- 执行命令**display pki entity [*entity-name*]**，查看PKI实体信息。
- 执行命令**display pki rsa local-key-pair { pem | pkcs12 } filename [password *password*]**，查看RSA密钥对信息。

- 执行命令**display pki rsa local-key-pair [name *key-name*] public [temporary]**，查看RSA公钥信息。
- 执行命令**display pki sm2 local-key-pair [name *key-name*] public**，查看SM2公钥信息。
- 执行命令**display pki realm [*realm-name*]**，查看PKI域的信息。
- 执行命令**display pki certificate ca realm *realm-name***，查看设备上已加载的CA证书的内容。
- 执行命令**display pki credential-storage-path**，查看证书的缺省保存路径。
- 执行命令**display pki ca-capability realm *realm-name***，查看PKI域相对应的CA能力。

----结束

16.7.2 申请和更新本地证书

背景信息

说明

设备出厂时已经在default域初始了CA和本地证书，可以执行命令**display pki certificate local realm default**查看本地证书信息。

前置任务

在申请和更新本地证书之前，需完成[16.7.1 申请本地证书的预配置](#)。

配置流程

请根据CA提供的服务方式选择配置申请和更新本地证书的方式。

16.7.2.1 配置通过 SCEP 协议为 PKI 实体申请和更新本地证书

背景信息

配置通过SCEP协议为PKI实体申请本地证书，有两种方式：

- 自动触发申请和更新本地证书
如果本地证书需要的配置信息齐全并且设备没有本地证书时，将自动触发设备通过SCEP协议申请本地证书；或者当证书即将过期、已经过期、已到达指定百分比时，自动触发设备通过SCEP协议申请并更新证书。
- 手动触发申请本地证书
如果本地证书需要的配置信息齐全并且设备没有本地证书时，将手动触发设备通过SCEP协议申请本地证书，当证书即将过期、已经过期、已到达指定百分比时，不会自动触发设备通过SCEP协议申请并更新证书。

这两种方式申请本地证书时，设备都会先向CA获取CA证书保存到存储介质中并将CA证书自动导入设备的内存中，然后使用CA证书的公钥加密证书注册请求消息并发送给CA来申请本地证书，获取本地证书保存到存储介质中并将本地证书自动导入设备的内存中。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki file-format { der | pem }**，配置设备保存证书时的文件格式。

缺省情况下，设备保存证书时的文件格式为PEM。

步骤3 执行命令**pki realm realm-name**，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

缺省情况下，设备存在名称为**default**的PKI域，且该域只能修改不能删除。

PKI域是一个本地概念，一个设备上配置的PKI域对CA和其他设备是不可见的，每一个PKI域有单独的参数配置信息。

步骤4 执行命令**ca id ca-name**，配置PKI域信任的CA。

缺省情况下，系统未配置PKI域信任的CA。

*ca-name*通常指的是CA服务器的名称。

步骤5 执行命令**entity entity-name**，指定申请证书的PKI实体。

缺省情况下，系统未指定申请证书的PKI实体。

*entity-name*是一个已经通过**pki entity**命令创建的PKI实体。

步骤6 执行命令**rsa local-key-pair key-name**，配置使用SCEP方式申请证书时使用的RSA密钥对。

缺省情况下，系统未配置使用SCEP方式申请证书时使用的RSA密钥对。

*key-name*是一个已经通过**pki rsa local-key-pair create**命令创建的RSA密钥对。

步骤7 （可选）执行命令**key-usage { ike | ssl-client | ssl-server } ***，配置证书公钥用途属性。

缺省情况下，系统未配置证书公钥用途属性。

步骤8 （可选）执行命令**source { interface interface-type interface-number | ip-address }**，配置建立TCP连接使用的源地址。

缺省情况下，设备使用出接口的IP地址作为建立TCP连接的源地址。

如果指定接口，请确保该接口为三层接口，且接口下已经配置了IP地址。

步骤9 （可选）执行命令**enrollment-request specific**，配置向CA申请证书时，使用特定格式的证书请求消息。

缺省情况下，向CA申请证书时，使用标准格式的证书请求消息。

步骤10 （可选）执行命令**extension-request enterprise**，配置证书注册请求消息携带的扩展请求属性使用Verisign公司定义的对象ID。

缺省情况下，证书注册请求消息携带的扩展请求属性使用PKCS#9标准定义的对象ID。

证书申请者希望CA颁发的本地证书的扩展信息中携带Verisign公司定义的对象ID时，可以配置此步骤。

步骤11 （可选）执行命令**ssl-policy policy-name**，绑定SSL策略。

缺省情况下，系统在PKI域视图下未绑定SSL策略。

通过SCEP协议为PKI实体申请和更新本地证书时，如果CA服务器的URL配置为HTTPS方式，即以“https://”开头，需要先绑定SSL策略，否则证书申请会失败。SSL策略的配置请参见《AR300, AR700 配置指南-安全》中的“SSL配置”。

说明

V300R021C10及之后版本支持此功能。

步骤12 执行命令**enrollment-url [esc] url [interval minutes] [times count] [ra]**，配置CA服务器的URL。

缺省情况下，系统未配置CA服务器的URL。

配置时，需注意：

- 未配置**esc**参数时，URL地址格式为**http://server_location/ca_script_location**或**https://server_location/ca_script_location**。
其中，*server_location*目前支持IP地址和域名解析的表示方式。*ca_script_location*是在CA服务器主机上的应用程序脚本的路径。比如：服务器版本的Windows系统作为CA服务器时，URL的格式为**http://host.port/certsrv/mscep/mscep.dll**，其中*host*为CA服务器的IP地址，*port*为CA服务器的端口号。服务器的IP为10.137.145.158，端口为8080时，URL为**http://10.137.145.158:8080/certsrv/mscep/mscep.dll**。
- 配置**esc**参数时，支持以ASCII码形式输入包含“?”的URL地址。
关键字**esc**作用是支持以ASCII码形式输入包含“?”的URL地址，格式必须为“\x3f”，3f为字符“?”的16进制ASCII码。例如，如果用户想输入“http://***.com?page1”，则对应的URL为“http://***.com\x3fpage1”；如果用户想同时输入“?”和“\x3f”（http://www.***.com?page1\x3f），则对应的URL为“http://www.***.com\x3fpage1\x3f”。
- 如果在CA服务器使用手工方式处理证书请求，证书发布可能需要较长时间。申请证书的PKI实体需要周期性发送查询，以便在证书颁发后能够及时获取到证书。此时，可以增大**interval**和**times**参数来调整注册证书状态查询的时间间隔和最大查询次数。
- 配置**ra**参数时，指定RA审核PKI实体申请本地证书时的身份信息。缺省情况下，CA审核PKI实体申请本地证书时的身份信息。

步骤13 执行命令**enrollment-request signature message-digest-method { sha1 | sha-256 | sha-384 | sha-512 | sm3 }**，配置签名证书注册请求消息使用的摘要算法。

缺省情况下，签名证书注册请求消息使用的摘要算法为**sha-256**。

SHA1算法为不安全算法，建议使用SHA2算法。

PKI实体使用的摘要算法必须与CA服务器上的摘要算法一致。

步骤14 执行命令**password cipher password**，配置SCEP证书申请时使用的挑战密码，也是证书撤销密码。

缺省情况下，系统未配置SCEP证书申请时使用的挑战密码。

PKI实体使用的挑战密码必须与CA服务器上设置的密码一致。如果CA服务器不要求使用挑战密码，则不用配置挑战密码。

步骤15 执行命令**fingerprint { sha1 | sha256 } fingerprint**，配置对CA证书进行验证时使用的CA证书数字指纹。

缺省情况下，系统未配置对CA证书进行验证时使用的CA证书数字指纹。

*fingerprint*参数需要通过离线的方式从CA服务器上获取。例如，当Windows Server 2008作为CA服务器时，可以通过登录网页http://host:port/certsrv/mscep_admin/获得CA证书指纹信息，其中host为CA服务器的IP地址，port为CA服务器的端口号。

步骤16 配置申请和更新本地证书的方式，请根据情况选择配置。

- 配置自动触发申请和更新本地证书。
执行命令**auto-enroll** [*percent*] [**regenerate** [*key-bit*]] [**updated-effective**]，开启证书自动注册和更新功能。
缺省情况下，证书自动注册和更新功能处于关闭状态。
- 配置手动触发申请本地证书。
 - a. 执行命令**quit**，返回至系统视图。
 - b. 执行命令**pki enroll-certificate realm** *realm-name* [**password** *password*]，配置手工触发设备申请证书。
如果配置了**password**命令，这里的**password**参数可以不用。如果都配置，这里配置的**password**优先级高。

----结束

16.7.2.2 配置通过 CMPv2 协议为 PKI 实体申请和更新本地证书

背景信息

当设备可以访问CA，并且CA支持CMPv2协议时，可选择此方式申请和更新本地证书。

通过CMPv2协议申请本地证书有两种情况：

- 首次申请本地证书IR（Initialization Request）
首次证书申请适用于设备第一次向CA申请证书的情况。在这种情况下，设备提供以下两种向CMPv2服务器进行身份认证的方式。
 - 消息认证码方式：设备和CMPv2服务器共享一对消息认证码的参考值和秘密值。在进行首次证书申请的时候，设备会将这对参考值和秘密值加入到请求报文当中发送到CMPv2服务器，CMPv2服务器通过验证参考值和秘密值来鉴定设备的身份。
 - 签名方式：通过CMPv2协议的IR请求，向CA发起证书请求时，设备使用其他CA颁发的证书相对应的私钥来签名保护。
- 为其他设备申请本地证书CR（Certification Request）
证书申请适用于当设备已经有了CA所颁发的本地证书，而需要申请额外的证书的情况。在这种情况下，设备会使用已有的证书作为身份认证的手段。

通过CMPv2协议更新本地证书有两种方式：

- 手工更新证书，即密钥更新请求KUR（Key Update Request）
密钥更新请求又称为证书更新请求，是对设备已有的证书（尚未过期且没有被吊销）进行更新操作。在更新过程中，使用现有的证书作为身份认证的手段。更新操作可以使用新的公钥，也可以使用原来的公钥。
通过IR方式申请本地证书，安全性较低，建议通过KUR方式更新本地证书及密钥对。
- 自动更新证书
为了避免业务的中断，在有效期截止前必须申请新的证书，而使用手工更新证书的方式容易出现忘记更新证书的情况。设备支持证书的自动更新功能，当系统检

测到时间超过了设置的证书自动更新时间之后，会自动向CMPv2服务器发起证书的更新请求。申请的新证书会同时替换存储介质中的证书文件和内存中对应的证书，业务不会中断。

此方式可以对IR方式申请的本地证书或KUR方式更新的本地证书进行自动更新。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki file-format { der | pem }**，配置设备保存证书时的文件格式。

缺省情况下，设备保存证书时的文件格式为PEM。

步骤3 执行命令**pki realm realm-name**，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

缺省情况下，系统未创建PKI域。

步骤4 执行命令**quit**，返回至系统视图。

步骤5 执行命令**pki cmp session session-name**，创建CMP会话并进入CMP会话视图，或者直接进入CMP会话视图。

缺省情况下，系统未创建CMP会话。

CMP会话是一个本地概念，一个设备上配置的CMP会话对CA和其他设备是不可见的。

步骤6 执行命令**cmp-request entity entity-name**，配置设备使用CMPv2方式申请证书时使用的PKI实体名称。

缺省情况下，系统未配置CMPv2方式申请证书时使用的PKI实体名称。

步骤7 执行命令**cmp-request ca-name ca-name**，为CMP会话配置CA的名称。

缺省情况下，系统未配置CMP会话下的CA名称。

配置的CA名称中各个字段的顺序必须要和实际CA证书中的顺序保持一致，否则CMPv2服务器会认为是错误的。

步骤8 执行命令**cmp-request server url [esc] url-addr**，配置CMPv2服务器的URL。

缺省情况下，系统未配置CMPv2服务器的URL。

*url-addr*可以设置为IP地址形式或域名形式，如果设置为域名形式，必须在PKI实体上正确配置DNS，使PKI实体可以通过DNS服务器解析域名。

步骤9 执行命令**cmp-request rsa local-key-pair key-name [regenerate [key-bit]]**，配置CMPv2方式申请证书时使用的RSA密钥对。

缺省情况下，系统未配置CMPv2方式申请证书时使用的RSA密钥对。

如果配置了**regenerate**参数，则证书自动更新时，系统会生成新的RSA密钥对去申请新证书，并且用新的证书和RSA密钥对替换原有的证书和RSA密钥对。否则证书自动更新时，系统会继续使用原来的RSA密钥对。

步骤10 执行命令**cmp-request realm realm-name**，配置使用CMPv2方式申请证书时使用的域名称。

缺省情况下，CMP服务器证书未指定PKI域。

步骤11 （可选）执行命令**cmp-request verification-cert** *cert-file-name*，配置验证CA响应签名的证书文件。

缺省情况下，系统未配置验证CA响应签名的证书文件。

- 如果配置了此命令，并且服务器的响应报文是签名的方式时，则设备使用该命令行配置的证书来验证服务器的响应签名。此处配置的证书为CA证书，即CA自身的证书。
- 如果未配置此命令，并且服务器的响应报文是签名的方式时，则依据设备以及服务器响应中的证书构建证书链，验证服务器的响应签名；如果服务器使用消息认证码方式做保护时，则设备使用配置的消息认证码来验证服务器的响应报文，不受该命令配置影响。

步骤12 请根据实际情况选择配置来申请本地证书。

- 首次申请本地证书（IR）
 - a. 执行命令**cmp-request origin-authentication-method** { **message-authentication-code** | **signature** }，配置使用CMPv2协议进行首次证书申请（IR）的认证方式。

缺省情况下，使用CMPv2协议进行首次证书申请（IR）的认证方式为消息认证码方式。

 - **message-authentication-code**表示消息认证码方式。选择此方式时请执行**步骤12.b**。
 - **signature**表示签名方式。选择此方式时请执行**步骤12.c**。
 - b. 执行命令**cmp-request message-authentication-code** *reference-value* *secret-value*，配置消息认证码的参考值和秘密值。

缺省情况下，系统未配置消息认证码的参考值和秘密值。
消息认证码的参考值和秘密值，需要用户以带外方式从CMPv2服务器上获取。
 - c. 执行命令**cmp-request authentication-cert** *cert-name*，配置CMPv2请求中用于证明身份的证书。

缺省情况下，系统未配置CMPv2请求中用于证明身份的证书。
此证书是额外证书，并且必须由受CA信任的证书申请机构为设备颁发。
 - d. 执行命令**quit**，返回至系统视图。
 - e. 执行命令**pki cmp initial-request session** *session-name*，根据CMP会话的配置信息向CMPv2服务器进行首次证书申请（IR）。

配置后，系统首先会检查CMP会话中的配置是否可以进行了证书申请。如果条件不满足，会给出错误的提示信息。如果条件满足，会依据配置内容发起首次证书请求。申请下来的证书将以文件的形式保存到存储介质中，不会执行导入内存的操作。同时，若服务器端在响应中给出CA证书，则CA证书也会以文件形式保存起来。
- 为其他设备申请本地证书（CR）
 - a. 执行命令**cmp-request authentication-cert** *cert-name*，配置CMPv2请求中用于证明身份的证书。

缺省情况下，系统未配置CMPv2请求中用于证明身份的证书。
此证书是CA已经颁发给设备的本地证书。
 - b. 执行命令**quit**，返回至系统视图。

- c. 执行命令**pki cmp certificate-request session *session-name***，根据CMP会话的配置信息向CMPv2服务器进行证书申请（CR）。

配置后，系统首先会检查CMP会话中的配置是否可以继续进行证书更新申请。如果条件不满足，会给出错误的提示信息。如果条件满足，会依据配置内容发起证书更新请求。申请下来的证书将以文件的形式保存到存储介质中，不会执行导入内存的操作。

步骤13 请根据实际情况选择配置来更新本地证书。

- 手工更新本地证书（KUR）
 - a. 执行命令**pki cmp session *session-name***，直接进入CMP会话视图。
 - b. 执行命令**cmp-request authentication-cert *cert-name***，配置CMPv2请求中用于证明身份的证书。
缺省情况下，系统未配置CMPv2请求中用于证明身份的证书。
此证书是CA已经颁发给设备的本地证书，同时也是将要被更新的本地证书。
 - c. 执行命令**quit**，返回至系统视图。
 - d. 执行命令**pki cmp keyupdate-request session *session-name***，根据CMP会话的配置信息向CMPv2服务器进行密钥更新请求（KUR）。
向CMPv2服务器进行密钥更新请求时，同时也会重新申请本地证书。
配置后，系统首先会检查CMP会话中的配置是否可以继续进行证书更新申请。如果条件不满足，会给出错误的提示信息。如果条件满足，会依据配置内容发起证书更新请求。申请下来的证书将以文件的形式保存到存储介质中，不会执行导入内存的操作。
- 自动更新证书
 - a. 执行命令**pki cmp session *session-name***，直接进入CMP会话视图。
 - b. 执行命令**cmp-request authentication-cert *cert-name***，配置CMPv2请求中用于证明身份的证书。
缺省情况下，系统未配置CMPv2请求中用于证明身份的证书。
此证书是CA已经颁发给设备的本地证书，同时也是将要被更新的本地证书。
 - c. 执行命令**certificate auto-update enable**，开启使用CMPv2方式自动更新证书功能。
缺省情况下，使用CMPv2方式自动更新证书功能处于关闭状态。
 - d. 执行命令**certificate update expire-time *valid-percent***，配置证书自动更新的时间，以当前使用证书有效期的百分比形式体现。
缺省情况下，证书更新时间的默认百分比是50%。
配置后，当系统检测到时间达到*valid-percent*时，会自动发起证书更新请求，并依据**cmp-request rsa local-key-pair**命令的配置决定是否创建新的RSA密钥对。申请到新的证书后，系统会使用新的证书和RSA密钥对替换原有的证书和RSA密钥对。
 - e. 执行命令**quit**，返回至系统视图。

步骤14 （可选）执行命令**undo pki cmp poll-request session *session-name***，取消正在进行的CMP轮询请求。

当客户端发起证书相关的请求时，如果服务器不能够马上给出结果，服务器会让客户端每隔一段时间发起一次轮询请求，直到给出最终的结果为止。如果用户不想继续等待，可以取消正在进行的CMP轮询请求，从而取消本次的证书申请操作。

----结束

16.7.2.3 配置为 PKI 实体离线申请本地证书

背景信息

如果CA服务器不支持SCEP和CMPv2协议，可以配置离线申请本地证书。用户在设备上生成证书请求文件，然后通过Web、磁盘、电子邮件等带外方式将证书申请文件发送给CA，向CA申请本地证书。完成申请后，还需从存放本地证书的服务器上下载证书，保存到设备的存储介质中。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki realm *realm-name***，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

缺省情况下，设备存在名称为**default**的PKI域，且该域只能修改不能删除。

PKI域是一个本地概念，一个设备上配置的PKI域对CA和其他设备是不可见的，每一个PKI域有单独的参数配置信息。

步骤3 执行命令**entity *entity-name***，指定申请证书的PKI实体。

缺省情况下，系统未指定申请证书的PKI实体。

*entity-name*是一个已经通过**pki entity**命令创建的PKI实体。

步骤4 执行命令**rsa local-key-pair *key-name***或执行命令**sm2 local-key-pair *key-name***，配置使用离线方式申请证书时使用的RSA/SM2密钥对。

缺省情况下，系统未配置使用离线方式申请证书时使用的RSA/SM2/密钥对。

步骤5 执行命令**enrollment-request signature message-digest-method { sha1 | sha-256 | sha-384 | sha-512 | sm3 }**，配置签名证书注册请求消息使用的摘要算法。

缺省情况下，签名证书注册请求消息使用的摘要算法为**sha-256**。

SHA1算法为不安全算法，建议使用SHA2算法。

PKI实体使用的摘要算法必须与CA服务器上的摘要算法一致。

步骤6 （可选）执行命令**key-usage { ike | ssl-client | ssl-server } ***，配置证书公钥用途属性。

缺省情况下，系统未配置证书公钥用途属性。

步骤7 （可选）执行命令**enrollment-request specific**，配置向CA申请证书时，使用特定格式的证书请求消息。

缺省情况下，向CA申请证书时，使用标准格式的证书请求消息。

步骤8 （可选）执行命令**extension-request enterprise**，配置证书注册请求消息携带的扩展请求属性使用Verisign公司定义的对象ID。

缺省情况下，证书注册请求消息携带的扩展请求属性使用PKCS#9标准定义的对象ID。

证书申请者希望CA颁发的本地证书的扩展信息中携带Verisign公司定义的对象ID时，可以配置此步骤。

步骤9 执行命令**quit**，返回至系统视图。

步骤10 执行命令**pki file-format { der | pem }**，配置设备保存证书和证书请求时的文件格式。

缺省情况下，设备保存证书和证书请求时的文件格式为PEM。

步骤11 执行命令**pki enroll-certificate realm *realm-name* pkcs10 [filename *filename*] [password *password*]**，配置以PKCS#10格式保存证书申请信息到文件中。

PKI实体使用的挑战密码必须与CA服务器上设置的密码一致。如果CA服务器不要求使用挑战密码，则不用配置挑战密码。

步骤12 通过Web、磁盘、电子邮件等带外方式将证书申请文件发送给CA，向CA申请本地证书。

----结束

16.7.2.4 检查申请和更新本地证书的配置结果

前提条件

已经完成申请和更新本地证书的所有配置。

操作步骤

- 执行命令**display pki realm [*realm-name*]**，查看PKI域的信息。
- 执行命令**display pki credential-storage-path**，查看证书的缺省保存路径。
- 执行命令**display pki certificate enroll-status [realm *realm-name*]**，查看证书的注册状态。
- 执行命令**display pki cert-req filename *file-name***，查看证书请求文件的内容。
- 执行命令**display pki cmp statistics [session *session-name*]**，查看CMP会话的统计信息。
- 执行命令**display pki certificate { ca | local } realm *realm-name***，查看设备上已加载的CA证书和本地证书的内容。

----结束

16.7.3 （可选）下载本地证书

背景信息

通过SCEP或CMPv2协议申请本地证书时，设备会自动下载本地证书。仅当离线申请本地证书时，才需要下载本地证书。

通常采用以下方式获得本地证书，设备采用哪种方式下载证书，取决于CA服务器提供的服务方式：

- 通过HTTP协议从Web服务器上下载本地证书，将本地证书下载到设备的存储介质中。
- 通过LDAP协议从存放证书的服务器上本地证书，将本地证书下载到设备的存储介质中。
- 通过带外方式（Web、磁盘、电子邮件等）获得本地证书后，上传到设备的存储介质中。

前置任务

已经完成本地证书的离线申请，本地证书已经在CA上注册成功。

操作步骤

- 通过HTTP方式下载本地证书。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**pki http [esc] url-address save-name**，配置通过HTTP方式下载本地证书。

*url-address*必须包含完整的证书文件及扩展名，例如http://10.1.1.1:8080/cert.cer。如果设置为域名方式，必须保证该域名可以正常解析。
- 通过LDAP方式下载本地证书。
 - a. 执行命令**system-view**，进入系统视图。
 - b. 执行命令**pki ldap ip ip-address port port version version [attribute attr-value] [authentication ldap-dn ldap-password] save-name dn dn-value**，配置通过LDAP方式下载本地证书。
- 通过带外方式下载本地证书。

用户通过Web、磁盘、电子邮件等方式获得本地证书后，需要手工上传到设备的存储介质中。也可以选择通过管理PC下载证书后，使用SFTP或Web方式上传到设备的存储介质中。

----结束

检查配置结果

- 执行命令**display pki credential-storage-path**，查看证书的缺省保存路径。
- 执行命令**dir（用户视图）**，查看存储器中的本地证书文件。

16.7.4（可选）安装本地证书

背景信息

下载的本地证书只有导入到设备的内存中才可以正常生效，并且设备会将导入内存证书文件保存到缺省目录下的**ca_config.ini**文件中，在重启后可以自动加载文件中记录的证书文件。

前置任务

已经完成本地证书的下载，证书文件已经保存到设备的存储介质中。

说明

请确保本地证书文件不超过1M，避免安装失败。

当通过CMPv2协议或离线申请本地证书时，需要手动安装本地证书。设备通过SCEP协议申请本地证书会自动安装本地证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令 **pki import-certificate { local realm *realm-name* { der | pkcs12 | pem } [filename *filename*] [replace] [no-check-validate] [no-check-hash-alg] | realm *realm-name* pem terminal password *password* }** 或执行命令 **pki import-certificate local realm *realm-name* pkcs12 filename *filename* [no-check-validate] [no-check-hash-alg] password *password***，将本地证书导入到设备的内存中。

证书及其密钥对有两种存在形式，一种是证书文件中包含密钥对文件，两者以一个文件的形式存在；另一种是证书和密钥对相互独立以两个文件形式存在。不同形式下，将其导入内存所使用的方法不同。

- 证书文件中包含密钥对文件。

执行命令 **pki import rsa-key-pair** 一次导入证书文件和密钥对文件。

说明

证书文件中包含密钥对文件时，执行命令 **pki import-certificate** 只能导入证书文件，密钥对文件不会被导入。如果需要导入密钥对文件，可执行命令 **pki import rsa-key-pair** 将密钥对继续导入。

- 证书文件和密钥对文件独立存在。

- a. 导入证书文件。

执行命令 **pki import-certificate** 导入证书文件。

- b. 导入密钥对文件。

执行命令 **pki import rsa-key-pair** 导入密钥对文件。

步骤3 （可选）执行命令 **pki set-certificate expire-prewarning *day***，配置内存中的本地证书的过期预告警时间。

缺省情况下，内存中的本地证书的过期预告警时间为90天。

----结束

后续处理

- 如果需要把本地证书拷贝到其他设备上使用，可以执行命令 **pki export-certificate local realm *realm-name* { der | pem | pkcs12 }**，将本地证书导出到设备的存储介质中。然后，用户可以通过FTP/SFTP取出本地证书。
- 如果需要把系统缺省内置的本地证书拷贝到其他设备上使用，可以执行命令 **pki export-certificate default local filename *filename***，将系统缺省内置的本地证书导出到设备存储介质中。然后，用户可以通过FTP/SFTP取出本地证书。

检查配置结果

执行命令 **display pki certificate local realm *realm-name***，查看设备上已加载的本地证书的内容。

16.7.5 验证 CA 证书和本地证书

前置任务

在验证证书之前，需完成 **16.7.4（可选）安装本地证书**。

配置流程

请按照以下顺序进行配置。对于可选步骤，请根据情况选择配置。

16.7.5.1 配置检查本地证书状态

背景信息

当验证对端实体的本地证书时，经常需要检查对端实体的本地证书是否有效，例如对端实体的本地证书是否过期、是否被加入CRL。通常检查证书状态的方式有三种：CRL方式、OCSP方式、None方式。

- CRL方式

如果CA支持作为CRL发布点CDP（CRL Distribution Point），则当CA颁发证书时，在证书中会包含CDP信息，用以描述获取该证书CRL的途径和方式。PKI实体利用CDP中指定的机制（HTTP、LDAP方式）和地址来下载CRL。

如果PKI实体配置了CDP的URL地址，该地址将覆盖证书中携带的CDP信息，PKI实体使用配置的URL来获取CRL。如果CA不支持作为CDP，则PKI实体可以使用SCEP方式下载CRL。

当PKI实体验证本地证书时，先查找本地内存的CRL，如果本地内存没有CRL，则需下载CRL并安装到本地内存中，如果对端实体的本地证书在CRL中，表示此证书已被撤销。

- OCSP方式

在IPSec场景中，PKI实体间使用证书方式进行IPSec协商时，可以通过OCSP方式实时检查对端实体的证书状态。

OCSP克服了CRL的主要缺陷：PKI实体必须经常下载CRL以确保列表的更新。当PKI实体访问OCSP服务器时，会发送一个对于证书状态信息的请求。OCSP服务器会回复一个“有效”、“过期”或“未知”的响应。

- 有效表示证书没有被撤销。
- 过期表示证书已被撤销。
- 未知表示OCSP服务器不能判断请求的证书状态。

- None方式

如果PKI实体没有可用的CRL和OCSP服务器，或者不需要检查PKI实体的本地证书状态，可以采用None方式，即不检查证书是否被撤销。

操作步骤

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**pki realm *realm-name***，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

缺省情况下，设备存在名称为**default**的PKI域，且该域只能修改不能删除。

3. 执行命令**certificate-check { { *crl* | *ocsp* } * [*none*] | *none* }**，配置PKI域中证书吊销状态的检查方式。

缺省情况下，PKI域中证书吊销状态的检查方式为CRL。

如果配置了多种吊销状态的检查方式，会按照配置的先后顺序执行，当前一种方式不可用（如服务器连接不上）时才会使用后边的方式。如果选用了不检查（*none*），当前面配置的方式均不可用时，认为证书有效。以配置了**certificate-check *crl ocsp none***命令为例，先使用CRL方式检查证书是否有效，如果CRL方式不可用，使用OCSP方式，如果两种方式都不可用，则认为证书是有效的。

4. 请根据CA提供的服务方式选择配置检查对端实体本地证书状态的方式。
 - 自动更新CRL方式
 - 手动更新CRL方式
 - OCSP方式

自动更新 CRL 方式

1. 执行命令**quit**，返回至系统视图。
2. （可选）执行命令**pki file-format { der | pem }**，配置设备保存CRL时的文件格式。
缺省情况下，设备保存CRL时的文件格式为PEM。
3. 执行命令**pki realm realm-name**，直接进入PKI域视图。
4. 执行命令**crl auto-update enable**，开启CRL自动更新功能。
缺省情况下，CRL自动更新功能处于开启状态。
5. 执行命令**crl update-period interval**，配置CRL自动更新的时间间隔。
缺省情况下，CRL自动更新的时间间隔为8小时。
6. 请根据CA提供的服务方式选择配置自动更新CRL方式。
 - 通过SCEP方式自动更新CRL。
 - i. 执行命令**crl scep**，配置使用SCEP方式自动更新CRL。
缺省情况下，使用HTTP方式自动更新CRL。
 - ii. 执行命令**cdp-url [esc] url-addr**，配置CRL发布点的URL。
缺省情况下，系统未配置CRL发布点的URL。
 - 通过HTTP方式自动更新CRL。
 - i. 执行命令**crl http**，配置使用HTTP方式自动更新CRL。
缺省情况下，使用HTTP方式自动更新CRL。
 - ii. 执行命令**cdp-url [esc] url-addr**，配置CRL发布点的URL。或者执行命令**cdp-url from-ca**，配置从CA证书中获取CDP URL。
缺省情况下，系统未配置CRL发布点的URL。
 - 通过LDAP方式自动更新CRL。
 - i. 执行命令**crl ldap**，配置使用LDAP方式自动更新CRL。
缺省情况下，使用HTTP方式自动更新CRL。
 - ii. 执行命令**ldap-server { authentication ldap-dn ldap-password | ip ip-address [port port | version version] * }**，配置使用LDAP方式自动更新CRL。
缺省情况下，系统未配置LDAP服务器。
 - iii. 执行命令**crl ldap [attribute attr-value] dn dn-value**，配置向LDAP服务器获取CRL时使用的属性和标识符。
缺省情况下，系统未配置向LDAP服务器获取CRL时使用的属性和标识符。
 - 通过LDAPv3模板方式自动更新CRL。
 - i. 执行命令**quit**，返回系统视图。
 - ii. 执行命令**ldap-server template template-name**，创建LDAP服务器模板并进入LDAP服务器模板视图。

- 缺省情况下，设备上未配置LDAP服务器模板。
- iii. 执行命令**ldap-server authentication** *ip-address* [*port-number*]，创建LDAP认证服务器。
缺省情况下，未配置LDAP认证服务器。
 - iv. 执行命令**ldap-server authentication manager** *manager-dn* *password* [*repassword*]，配置LDAP服务器的管理员区别名和管理员密码。
缺省情况下，未配置LDAP认证服务器的管理员区别名和管理员密码。
配置后，可以执行命令**ldap-server authentication manager-password** *password* [*repassword*]，修改LDAP认证服务器的管理员密码。
 - v. 执行命令**quit**，返回系统视图。
 - vi. 执行命令**pki realm** *realm-name*，直接进入PKI域视图。
 - vii. 执行命令**crl ldap**，配置使用LDAP方式自动更新CRL。
缺省情况下，使用HTTP方式自动更新CRL。
 - viii. 执行命令**ldap-server-template** *attr-value*，在PKI域下引用LDAP服务器模板。
缺省情况下，PKI域下没有引用LDAP服务器模板。
*attr-value*参数是通过命令**ldap-server template**配置。
7. 执行命令**crl cache**，配置允许PKI域使用缓存中的CRL。
缺省情况下，系统允许PKI域使用缓存中的CRL。
8. （可选）立即更新CRL。
- a. 执行命令**quit**，返回至系统视图。
 - b. 执行命令**pki get-crl realm** *realm-name*，立即更新CRL。
立即更新CRL后，新的CRL会替换设备存储介质中原来的CRL，同时新的CRL也会被自动导入设备内存中替换原来的CRL。

手动更新 CRL 方式

- 1. 执行命令**quit**，返回至系统视图。
- 2. （可选）执行命令**pki file-format** { **der** | **pem** }，配置设备保存CRL时的文件格式。
缺省情况下，设备保存CRL时的文件格式为PEM。
- 3. 请根据CA提供的服务方式选择配置手动更新CRL方式。
 - 执行命令**pki http** [**esc**] *url-address* *save-name*，配置通过HTTP方式下载CRL。
*url-address*必须包含完整的证书文件及扩展名，例如http://10.1.1.1:8080/cert.cer cert.cer。如果设置为域名方式，必须保证该域名可以正常解析。
 - 执行命令**pki ldap ip** *ip-address* **port** *port* **version** *version* [**attribute** *attr-value*] [**authentication** *ldap-dn* *ldap-password*] *save-name* **dn** *dn-value*，配置通过LDAP方式下载CRL。
- 4. 执行命令**pki import-crl realm** *realm-name* **filename** *file-name*，将CRL导入设备的内存中。

OCSP 方式

1. （可选）执行命令 **source { interface interface-type interface-number | ip-address }**，配置建立TCP连接使用的源地址。
缺省情况下，设备使用出接口的IP地址作为建立TCP连接的源地址。
如果指定接口，请确保该接口为三层接口，且接口下已经配置了IP地址。
2. 执行命令 **ocsp url [esc] url-address**，配置OCSP服务器的URL。或者执行命令 **ocsp-url from-ca**，配置从CA证书的AIA选项中获取OCSP服务器的URL。
缺省情况下，系统未配置OCSP服务器的URL。
3. （可选）执行命令 **ocsp nonce enable**，配置PKI实体发送OCSP请求时带有Nonce扩展。
缺省情况下，PKI实体发送OCSP请求时带有Nonce扩展。
通过该功能可以增强PKI实体与OCSP服务器通信时的安全性和可靠性。配置后，PKI实体与OCSP服务器通信时发送的OCSP请求中带有Nonce扩展，内容为随机数。对于OCSP服务器发出的响应报文，可以不包含Nonce扩展，但是如果包含了Nonce扩展，则必须与OCSP请求中的Nonce扩展一致。
4. （可选）执行命令 **ocsp signature enable**，开启OCSP请求消息签名功能。
缺省情况下，OCSP请求消息签名功能处于关闭状态。
如果OCSP服务器要求对OCSP请求消息进行签名验证，设备需要配置本命令。
5. 执行命令 **quit**，返回至系统视图。
6. 执行命令 **pki import-certificate ocsp realm realm-name { der | pkcs12 | pem } [filename filename]** 或执行命令 **pki import-certificate ocsp realm realm-name pkcs12 filename filename password password**，将OCSP服务器证书导入到设备的存中。
7. 执行命令 **pki validate ocsp-server-certificate enable**，开启OCSP证书校验OCSP服务器报文的功能。
缺省情况下，OCSP证书校验OCSP服务器报文的功能处于关闭状态。
8. 执行命令 **pki ocsp response cache enable**，开启PKI实体缓存OCSP响应的功能。
缺省情况下，PKI实体缓存OCSP响应的功能处于关闭状态。
开启缓存OCSP响应功能后，PKI实体在使用OCSP检查证书的吊销状态时，会先查找缓存，如果查找失败则再向OCSP服务器发起请求。同时，PKI实体会将有效的OCSP响应缓存起来，以便下次查找。
OCSP响应是有生效期限的，开启缓存OCSP响应功能后，PKI实体会每隔1分钟刷新缓存的OCSP响应，清除其中过期的OCSP响应。
9. （可选）执行命令 **pki ocsp response cache number number**，配置PKI实体可以缓存的OCSP响应的最大数量。
缺省情况下，PKI实体可以缓存的OCSP响应的最大数量是2。
10. （可选）执行命令 **pki ocsp response cache refresh interval interval**，配置PKI实体刷新OCSP响应缓存的周期。
缺省情况下，PKI实体刷新OCSP响应缓存的周期为5分钟。

后续处理

- 如果需要把OCSP服务器证书拷贝到其他设备上使用时，可以执行命令 **pki export-certificate ocsp realm realm-name { der | pem | pkcs12 }**，将OCSP服务器证书导出到设备的存储介质中。然后，可以通过文件传输协议取出证书。

- 如果OCSP服务器证书过期或者不使用时，可以执行命令**pki delete-certificate ocs *realm realm-name***，从内存中删除OCSP服务器证书。
- 如果CRL过期或者不使用时，可以执行命令**pki delete-crl *realm realm-name***，从内存中删除CRL。

16.7.5.2 配置检查 CA 证书和本地证书有效性

背景信息

在使用每一个证书之前，必须对证书进行验证以确保证书的合法性。证书验证包括对签发时间、签发者信息以及证书的有效性几方面进行验证。证书验证的核心是检查CA在证书上的签名，并确定证书仍在有效期内，而且未被撤销。

为完成证书验证，除了需要对端实体的本地证书外，本地设备需要下面的信息：CA证书、CRL、本地证书及其私钥及证书认证相关配置信息。

本地证书验证的主要过程如下：

1. 使用CA证书的公钥验证CA的签名是否正确。

为验证一个证书的合法性，首先需要获得颁发这个证书的CA的公钥（即获得CA证书），以便检查该证书上CA的签名。一个CA可以让另一个更高层次的CA来证明其证书的合法性，这样顺着证书链，验证证书就变成了一个迭代过程，最终这个链必须在某个“信任点”（一般是持有自签名证书的根CA或者是PKI实体信任的中间CA）处结束。

任何PKI实体，如果它们共享相同的根CA或子CA，并且已获取CA证书，都可以验证对端证书。一般情况下，当验证对端证书链时，验证过程在碰到第一个可信任的证书或CA机构时结束。

证书链的验证过程是一个从目标证书（待验证的PKI实体证书）到信任点证书逐层验证的过程。

2. 根据证书的有效期，验证证书是否过期。
3. 检查证书的状态，即通过CRL和None方式检查证书是否被撤销。

当用户需要验证本地设备的CA证书和本地证书的有效性时，可以执行以下步骤。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki validate-certificate { ca | local } *realm realm-name***，检查CA证书或本地证书的有效性。

pki validate-certificate ca命令只能验证根CA的CA证书有效性，不能验证从属CA的CA证书有效性。在多级CA的环境中，当设备上导入了多个CA证书时，只能使用**pki validate-certificate local**命令来验证从属CA的CA证书有效性。

步骤3 （可选）执行命令**pki *realm realm-name***，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

步骤4 （可选）执行命令**validate time disable**，配置PKI证书校验时不校验时间。

缺省情况下，PKI证书校验时进行时间校验。

----结束

16.7.5.3 检查验证 CA 证书和本地证书的配置结果

前提条件

已经完成验证CA证书和本地证书的所有配置。

操作步骤

- 执行命令**display pki realm** [*realm-name*]，查看PKI域的信息。
- 执行命令**display pki crl** { *realm realm-name* | *filename filename* }，查看设备中的CRL内容。
- 执行命令**display pki certificate ocsf realm** *realm-name*，查看设备上已加载的OCSP服务器证书的内容。
- 执行命令**display pki ocsf cache statistics**，查看OCSP响应缓存的统计信息。
- 执行命令**display pki ocsf server down-information**，查看设备上记录的OCSP服务器DOWN状态信息。
- 执行命令**display ldap-server template** [*template-name*]，查看LDAP服务器模板的配置信息。

----结束

16.7.6 删除本地证书

背景信息

本地证书过期或者重新申请新的证书时，可以删除本地证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki delete-certificate local realm** *realm-name*，从内存中删除本地证书。

----结束

16.7.7 配置 PKI 扩展功能

16.7.7.1 配置获取证书

背景信息

当PKI实体通过SCEP协议申请本地证书时，PKI实体可以向CA服务器查询并获取已颁发的证书至设备存储介质中。该证书可以是PKI实体自身的本地证书，也可以是CA证书，或其他PKI实体的本地证书。

获取CA证书时，设备会自动将CA证书导入到设备内存中；获取本地证书时，需要通过手工方式将其导入到设备内存中。

获取证书的目的有两个：

- 将CA颁发的与PKI实体所在安全域有关的证书存放到设备存储介质中，以提高证书的查询效率，减少向PKI证书存储库查询的次数。

- 为证书的验证做好准备。

操作步骤

步骤1 执行命令`system-view`，进入系统视图。

步骤2 执行命令`pki get-certificate { ca | local } realm realm-name`，获取证书至设备的存储介质中。

如果设备中存在相同的证书，则需要删除设备中的证书，否则会导致获取证书失败。

----结束

16.7.7.2 配置导入和释放对端实体的证书

背景信息

当采用数字信封认证方式时，如果设备作为数据发送者，设备上需要配置数据接收者的公钥。导入对端实体的证书即为获取对端实体的公钥的一种方法，该方法建立了用户身份信息与用户公钥的关联，安全性高，适合在大规模网络时部署。

当导入的对端实体的证书不需要使用时，可以将对端实体的证书释放。

操作步骤

- 导入对端实体的证书
 - a. 执行命令`system-view`，进入系统视图。
 - b. 执行命令`pki import-certificate peer peer-name { { der | pem | pkcs12 } filename [ filename ] | pem terminal }`或执行命令`pki import-certificate peer peer-name pkcs12 filename filename password password`，导入对端实体的证书到设备的内存中。
- 释放对端实体的证书
 - a. 执行命令`system-view`，进入系统视图。
 - b. 执行命令`pki release-certificate peer { name peer-name | all }`，释放对端实体的证书。

----结束

检查配置结果

执行命令`display pki peer-certificate { name peer-name | all }`，查看已导入的对端实体证书。

16.7.7.3 配置自签名证书或设备本地证书

背景信息

如果设备无法向CA申请本地证书，可以通过设备生成自签名证书或设备本地证书后，生成的证书以文件形式保存在存储器中，实现简单的证书颁发功能。用户可以将证书导出供其他设备使用。

- 自签名证书是设备为自己颁发的证书，即证书颁发者和证书主体相同。

- 设备本地证书是设备根据CA证书给自己颁发的证书，证书颁发者是CA。

说明

设备不支持对其生成的自签名证书进行生命周期管理（如证书更新、证书撤销等），为了确保设备和证书的安全，建议用户替换为自己的本地证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki create-certificate [self-signed] filename file-name**，创建自签名证书或设备本地证书。

配置时，会提示用户输入证书的一些信息，比如PKI实体属性、证书文件名称、证书有效期和RSA密钥长度等。

指定**self-signed**参数时，创建自签名证书。不指定此参数时，创建设备本地证书。

创建的自签名证书或设备本地证书的文件格式为PEM。

----结束

16.7.7.4 配置 PKI 加入到指定的 VPN 内

背景信息

当CA等服务器位于某个VPN内时，为了让设备可以与这些服务器进行通信以实现证书的获取或有效性校验等功能，此时需配置PKI域加入到指定的VPN内。

操作步骤

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**pki realm realm-name**，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

缺省情况下，设备存在名称为**default**的PKI域，且该域只能修改不能删除。

PKI域是一个本地概念，一个设备上配置的PKI域对CA和其他设备是不可见的，每一个PKI域有单独的参数配置信息。

3. 执行命令**vpn-instance vpn-instance-name**，将PKI加入到指定的VPN内。

缺省情况下，系统未将PKI加入到任何VPN内。

vpn-instance-name参数可通过命令**ip vpn-instance**配置。

16.8 维护 PKI

16.8.1 查看 PKI 信息

背景信息

在日常维护工作中，了解PKI相关信息时，可以在对应视图下选择执行以下命令查看证书等信息。

操作步骤

- 执行命令**display pki certificate enroll-status [realm *realm-name*]**，查看证书的注册状态。
- 执行命令**display pki cmp statistics [session *session-name*]**，查看CMP会话的统计信息。
- 执行命令**display pki ocsp cache statistics**，查看OCSP响应缓存的统计信息。
- 执行命令**display pki ocsp server down-information**，查看设备上记录的OCSP服务器DOWN状态信息。
- 执行命令**display pki certificate { ca | local | ocsp } realm *realm-name***，查看设备上已加载的CA证书、本地证书或者OCSP服务器证书的内容。
- 执行命令**display pki certificate default { ca | local }**，查看设备上缺省的CA证书和本地证书的内容。
- 执行命令**display pki peer-certificate { name *peer-name* | all }**，查看已导入的对端实体证书。
- 执行命令**display pki ocsp cache detail**，查看OCSP响应缓存的详细信息。

----结束

16.8.2 清除 PKI 信息

背景信息

清空PKI信息后，以前的信息将无法恢复，务必仔细确认。请在用户视图下执行以下命令。

操作步骤

- 执行命令**reset pki cmp statistics [session *session-name*]**，清除CMP会话的统计信息。
- 执行命令**reset pki ocsp response cache**，清除OCSP响应缓存。
- 执行命令**reset pki ocsp server down-information [url [*esc*] *url-addr*]**，清除设备上记录的OCSP服务器DOWN状态信息。

----结束

16.9 PKI 配置举例

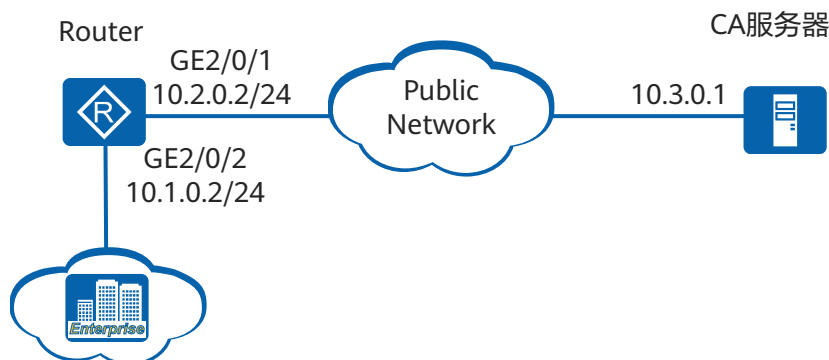
16.9.1 配置通过 SCEP 协议自动为 PKI 实体申请本地证书示例

组网需求

如图16-11所示，某企业在网络边界处部署了Router作为出口网关，Router向公网上的CA服务器在线申请本地证书。

用户希望通过简单快捷的方式为PKI实体申请本地证书，申请成功后能自动将证书导入到设备内存中，而且证书过期时，能自动更新证书。此时，可以配置通过SCEP协议自动为PKI实体申请本地证书实现上述需求。

图 16-11 配置通过 SCEP 协议自动为 PKI 实体申请本地证书组网图



说明

本举例只列出了申请证书时Router侧的相关配置，CA服务器的部署和配置请参见相关产品手册。这里的CA服务器以Windows Server 2008自带的“证书服务”，并安装了SCEP插件为例进行说明。

配置思路

采用如下思路配置通过SCEP协议自动为PKI实体申请本地证书：

1. 配置接口的IP地址及到CA服务器的静态路由，实现Router和CA服务器之间路由互通。
2. 创建RSA密钥对，实现申请本地证书时携带公钥。
3. 配置PKI实体，实现申请本地证书时携带PKI实体信息用来标识PKI实体的身份。
4. 通过SCEP协议申请和自动更新证书，实现自动安装证书，并且证书过期时，能自动更新证书。

数据准备

申请证书前需要以离线方式从CA服务器上获取数字指纹和挑战密码。这里假设数字指纹为

“e71add0744360e91186b828412d279e06dcc15a4ab4bb3d13842820396b526a0”和挑战密码为“6AE73F21E6D3571D”。

本文以Windows Server 2008作为CA服务器为例，可以通过登录网页http://host:port/certsrv/mscep_admin/获得CA证书指纹信息和挑战密码，其中`host`为CA服务器的IP地址，`port`为CA服务器的端口号。

操作步骤

步骤1 配置接口的IP地址及到CA服务器的静态路由。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] interface gigabitethernet 2/0/1
[Router-GigabitEthernet2/0/1] ip address 10.2.0.2 255.255.255.0
[Router-GigabitEthernet2/0/1] quit
[Router] interface gigabitethernet 2/0/2
[Router-GigabitEthernet2/0/2] ip address 10.1.0.2 255.255.255.0
[Router-GigabitEthernet2/0/2] quit
[Router] ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
```

步骤2 创建RSA密钥对。

创建一个4096位的RSA密钥对rsa_scep，并设置为可以从设备上导出。

```
[Router] pki rsa local-key-pair create rsa_scep exportable
Info: The name of the new key-pair will be: rsa_scep
The size of the public key ranges from 2048 to 4096.
Input the bits in the modules:4096
Generating key-pairs...      .....+++
.....+++
```

步骤3 配置PKI实体，标识申请证书PKI实体的身份信息。

配置PKI实体为用户01。

```
[Router] pki entity user01
[Router-pki-entity-user01] common-name hello
[Router-pki-entity-user01] country cn
[Router-pki-entity-user01] email user@test.abc.com
[Router-pki-entity-user01] fqdn test.abc.com
[Router-pki-entity-user01] ip-address 10.2.0.2
[Router-pki-entity-user01] state jiangsu
[Router-pki-entity-user01] organization
[Router-pki-entity-user01] organization-unit info
[Router-pki-entity-user01] quit
```

步骤4 通过SCEP协议申请和更新证书。

```
[Router] pki realm abc
[Router-pki-realm-abc] ca id ca_root
[Router-pki-realm-abc] entity user01
[Router-pki-realm-abc] fingerprint sha256
e71add0744360e91186b828412d279e06dcc15a4ab4bb3d13842820396b526a0
[Router-pki-realm-abc] enrollment-url http://10.3.0.1:80/certsrv/mscep/mscep.dll ra
[Router-pki-realm-abc] rsa local-key-pair rsa_scep
[Router-pki-realm-abc] enrollment-request signature message-digest-method sha-384
[Router-pki-realm-abc] password cipher YsHsjx_202206
```

步骤5 开启证书自动注册和更新功能，指定证书有效期到60%时自动更新并同时更新RSA密钥。

```
[Router-pki-realm-abc] auto-enroll 60 regenerate 4096
[Router-pki-realm-abc] quit
```

申请本地证书时，设备会先获取CA证书并自动安装CA证书，然后再获取本地证书并自动安装本地证书。获取的CA证书和本地证书名称分别为abc_ca.cer和abc_local.cer。

步骤6 验证配置结果。

1. 证书申请成功后，可执行命令**display pki certificate local**查看已经导入内存的本地证书的内容。

```
[Router] display pki certificate local realm abc
The x509 object type is certificate:
Certificate:
Data:
  Version: 3 (0x2)
  Serial Number:
    48:65:aa:2a:00:00:00:00:3f:c6
  Signature Algorithm: sha1WithRSAEncryption
  Issuer: CN=ca_root
  Validity
    Not Before: Dec 21 11:46:10 2015 GMT
    Not After : Dec 21 11:56:10 2016 GMT
  Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
  Subject Public Key Info:
    Public Key Algorithm: rsaEncryption
    Public-Key: (4096 bit)
    Modulus:
      00:94:6f:49:bd:6a:f3:d5:07:ee:10:ee:4f:d3:06:
```



```
80:59:15:cb:a8:0a:b2:ba:c2:db:52:ec:e9:d1:a7:
72:de:ac:35:df:bb:e0:72:62:08:3e:c5:54:c1:ba:
4a:bb:1b:a9:d9:dc:e4:b6:4d:ca:b3:54:90:b6:8e:
15:a3:6e:2d:b2:9e:9e:7a:33:b0:56:3f:ec:bc:67:
1c:4c:59:c6:67:0f:a7:03:52:44:8c:53:72:42:bd:
6e:0c:90:5b:88:9b:2c:95:f7:b8:89:d1:c2:37:3e:
93:78:fa:cb:2c:20:22:5f:e5:9c:61:23:7b:c0:e9:
fe:b7:e6:9c:a1:49:0b:99:ef:16:23:e9:44:40:6d:
94:79:20:58:d7:e1:51:a1:a6:4b:67:44:f7:07:71:
54:93:4e:32:ff:98:b4:2b:fa:5d:b2:3c:5b:df:3e:
23:b2:8a:1a:75:7e:8f:82:58:66:be:b3:3c:4a:1c:
2c:64:d0:3f:47:13:d0:5a:29:94:e2:97:dc:f2:d1:
06:c9:7e:54:b3:42:2e:15:b8:40:f3:94:d3:76:a1:
91:66:dd:40:29:c3:69:70:6d:5a:b7:6b:91:87:e8:
bb:cb:a5:7e:ec:a5:31:11:f3:04:ab:1a:ef:10:e6:
f1:bd:d9:76:42:6c:2e:bf:d9:91:39:1d:08:d7:b4:
18:53
Exponent: 65537 (0x10001)
X509v3 extensions:
X509v3 Subject Alternative Name:
  IP Address:10.2.0.2, DNS:test.abc.com, email:user@test.abc.com
X509v3 Subject Key Identifier:
  15:D1:F6:24:EB:6B:C0:26:19:58:88:91:8B:60:42:CE:BA:D5:4D:F3
X509v3 Authority Key Identifier:
  keyid:B8:63:72:A4:5E:19:F3:B1:1D:71:E1:37:26:E1:46:39:01:B6:82:C
5
X509v3 CRL Distribution Points:

  Full Name:
    URI:file://\vasp-e6000-127.china..com\CertEnroll\ca_roo
t.crl
    URI:http://10.3.0.1:8080/certenroll/ca_root.crl

  Authority Information Access:
    CA Issuers - URI:http://vasp-e6000-127.china..com/CertEnro
ll/vasp-e6000-127.china..com_ca_root.crt
    OCSP - URI:file://\vasp-e6000-127.china..com\CertEnroll\va
sp-e6000-127.china..com_ca_root.crt

1.3.6.1.4.1.311.20.2:
  .0.I.P.S.E.C.I.n.t.e.r.m.e.d.i.a.t.e.O.f.f.l.i.n.e
Signature Algorithm: sha1WithRSAEncryption
d2:be:a8:52:6b:03:ce:89:f1:5b:49:d4:eb:2b:9f:fd:59:17:
d4:3c:f1:db:4f:1b:d1:12:ac:bf:ae:59:b4:13:1b:8a:20:d0:
52:6a:f8:a6:03:a6:72:06:41:d2:a7:7d:3f:51:64:9b:84:64:
cf:ec:4c:23:0a:f1:57:41:53:eb:f6:3a:44:92:f3:ec:bd:09:
75:db:02:42:ab:89:fa:c4:cd:cb:09:bf:83:1d:de:d5:4b:68:
8a:a6:5f:7a:e8:b3:34:d3:e8:ec:24:37:2b:bd:3d:09:ed:88:
d8:ed:a7:f8:66:aa:6f:b0:fe:44:92:d4:c9:29:21:1c:b3:7a:
65:51:32:50:5a:90:fa:ae:19:5f:c8:63:8d:a8:e7:c6:89:
2e:6d:c8:5b:2c:0c:cd:41:48:bd:79:74:0e:b8:2f:48:69:df:
02:89:bb:b3:59:91:7f:6b:46:29:7e:22:05:8c:bb:6a:7e:f3:
11:5a:5f:fb:65:51:7d:35:ff:49:9e:ec:d1:2d:7e:73:e5:99:
c6:41:84:0c:50:11:ed:97:ed:15:de:11:22:73:a1:78:11:2e:
34:e6:f5:de:66:0c:ba:d5:32:af:b8:54:26:4f:5b:9e:89:89:
2a:3f:b8:96:27:00:c3:08:3a:e9:e8:a6:ce:4b:5a:e3:97:9e:
6b:dd:f0:72

Pki realm name: abc
Certificate file name: abc_local.cer
Certificate peer name: -
```

2. 证书申请成功后，可执行命令**display pki certificate ca**查看已经导入内存的CA证书的内容。

```
[Router] display pki certificate ca realm abc
The x509 object type is certificate:
Certificate:
Data:
```

```
Version: 3 (0x2)
Serial Number:
0c:f0:1a:f3:67:21:44:9a:4a:eb:ec:63:75:5d:d7:5f
Signature Algorithm: sha1WithRSAEncryption
Issuer: CN=ca_root
Validity
  Not Before: Jun  4 14:58:17 2015 GMT
  Not After : Jun  4 15:07:10 2020 GMT
Subject: CN=ca_root
Subject Public Key Info:
  Public Key Algorithm: rsaEncryption
  Public-Key: (4096 bit)
  Modulus:
    00:d9:5f:2a:93:cb:66:18:59:8c:26:80:db:cd:73:
    d5:68:92:1b:04:9d:cf:33:a2:73:64:3e:5f:fe:1a:
    53:78:0e:3d:e1:99:14:aa:86:9b:c3:b8:33:ab:bb:
    76:e9:82:f6:8f:05:cf:f6:83:8e:76:ca:ff:7d:f1:
    bc:22:74:5e:8f:4c:22:05:78:d5:d6:48:8d:82:a7:
    5d:e1:4c:a4:a9:98:ec:26:a1:21:07:42:e4:32:43:
    ff:b6:a4:bd:5e:4d:df:8d:02:49:5d:aa:cc:62:6c:
    34:ab:14:b0:f1:58:4a:40:20:ce:be:a5:7b:77:ce:
    a4:1d:52:14:11:fe:2a:d0:ac:ac:16:95:78:34:34:
    21:36:f2:c7:66:2a:14:31:28:dc:7f:7e:10:12:e5:
    6b:29:9a:e8:fb:73:b1:62:aa:7e:bd:05:e5:c6:78:
    6d:3c:08:4c:9c:3f:3b:e0:e9:f2:fd:cb:9a:d1:b7:
    de:1e:84:f4:4a:7d:e2:ac:08:15:09:cb:ee:82:4b:
    6b:bd:c6:68:da:7e:c8:29:78:13:26:e0:3c:6c:72:
    39:c5:f8:ad:99:e4:c3:dd:16:b5:2d:7f:17:e4:fd:
    e4:51:7a:e6:86:f0:e7:82:2f:55:d1:6f:08:cb:de:
    84:da:ce:ef:b3:b1:d6:b3:c0:56:50:d5:76:4d:c7:
    fb:75
  Exponent: 65537 (0x10001)
X509v3 extensions:
  1.3.6.1.4.1.311.20.2:
    ...C.A
  X509v3 Key Usage: critical
    Digital Signature, Certificate Sign, CRL Sign
  X509v3 Basic Constraints: critical
    CA:TRUE
  X509v3 Subject Key Identifier:
    B8:63:72:A4:5E:19:F3:B1:1D:71:E1:37:26:E1:46:39:01:B6:82:C5
  X509v3 CRL Distribution Points:

  Full Name:
    URI:http://vasp-e6000-127.china..com/CertEnroll/ca_root.
crl
    URI:file://\\vasp-e6000-127.china..com\CertEnroll\ca_roo
t.crl

  1.3.6.1.4.1.311.21.1:
    ...
  Signature Algorithm: sha1WithRSAEncryption
  52:21:46:b8:67:c8:c3:4a:e7:f8:cd:e1:02:d4:24:a7:ce:50:
  be:33:af:8a:49:47:67:43:f9:7f:79:88:9c:99:f5:87:c9:ff:
  08:0f:f3:3b:de:f9:19:48:e5:43:0e:73:c7:0f:ef:96:ef:5a:
  5f:44:76:02:43:83:95:c4:4e:06:5e:11:27:69:65:97:90:4f:
  04:4a:1e:12:37:30:95:24:75:c6:a4:73:ee:9d:c2:de:ea:e9:
  05:c0:a4:fb:39:ec:5c:13:29:69:78:33:ed:d0:18:37:6e:99:
  bc:45:0e:a3:95:e9:2c:d8:50:fd:ca:c2:b3:5a:d8:45:82:6e:
  ec:cc:12:a2:35:f2:43:a5:ca:48:61:93:b9:6e:fe:7c:ac:41:
  bf:88:70:57:fc:bb:66:29:ae:73:9c:95:b9:bb:1d:16:f7:b4:
  6a:da:03:df:56:cf:c7:c7:8c:a9:19:23:61:5b:66:22:6f:7e:
  1d:26:92:69:53:c8:c6:0e:b3:00:ff:54:77:5e:8a:b5:07:54:
  fd:18:39:0a:03:ac:1d:9f:1f:a1:eb:b9:f8:0d:21:25:36:d5:
  06:de:33:fa:7b:c8:e9:60:f3:76:83:bf:63:c6:dc:c1:2c:e4:
  58:b9:cb:48:15:d2:a8:fa:42:72:15:43:ef:55:63:39:58:77:
  e8:ae:0f:34

Pki realm name: abc
```

```
Certificate file name: abc_ca.cer  
Certificate peer name: -
```

3. 配置证书自动更新功能后，当系统检测到时间已经超过了配置的当前证书有效期的60%之后，就会向SCEP服务器发起证书的更新请求。

由于配置命令**auto-enroll**时选择了**regenerate**参数，更新时系统会生成新的RSA密钥对去申请新证书。

----结束

配置文件

Router的配置文件

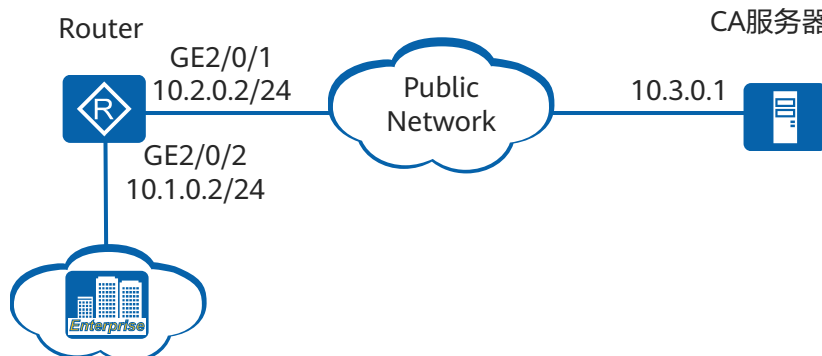
```
#  
sysname Router  
#  
pki entity user01  
country CN  
state jiangsu  
organization  
organization-unit info  
common-name hello  
fqdn test.abc.com  
ip-address 10.2.0.2  
email user@test.abc.com  
#  
pki realm abc  
ca id ca_root  
enrollment-url http://10.3.0.1:80/certsrv/mscep/mscep.dll ra  
entity user01  
fingerprint sha256 e71add0744360e91186b828412d279e06dcc15a4ab4bb3d13842820396b526a0  
rsa local-key-pair rsa_scep  
password cipher %^%#\c{UCn\RwO'<$oTEf1Q%rZp"U$(K{GGPvZN(qw,B%^%#  
auto-enroll 60 regenerate  
enrollment-request signature message-digest-method sha-384  
#  
interface GigabitEthernet2/0/1  
ip address 10.2.0.2 255.255.255.0  
interface GigabitEthernet2/0/2  
ip address 10.1.0.2 255.255.255.0  
#  
ip route-static 10.3.0.0 255.255.255.0 10.2.0.1  
#  
return
```

16.9.2 配置通过 CMPv2 协议为 PKI 实体首次申请本地证书示例

组网需求

如图16-12所示，某企业在网络边界处部署了Router作为出口网关，Router使用CMPv2协议向公网上的CA服务器在线首次申请证书，申请成功后自动将本地证书下载到设备存储介质中。

图 16-12 配置通过 CMPv2 协议为 PKI 实体首次申请本地证书组网图



说明

本举例只列出了申请证书时Router侧的相关配置，CA服务器的部署和配置请参见相关产品手册。

只支持通过HTTP+CMPv2方式申请证书，不支持HTTPS+CMPv2方式。

配置思路

采用如下思路配置通过CMPv2协议为PKI实体首次申请本地证书：

1. 配置接口的IP地址及到CA服务器的静态路由，实现Router和CA服务器之间路由互通。
2. 创建RSA密钥对，实现申请本地证书时携带公钥。
3. 配置PKI实体，实现申请本地证书时携带PKI实体信息用来标识PKI实体的身份。
4. 通过CMPv2协议申请和自动更新证书，并使用消息认证码来验证消息，实现自动下载CA和本地证书。
5. 安装CA和本地证书，实现证书生效，即设备可以使用证书来保护通信。

数据准备

为完成此配置示例，需准备如下的数据：

- CA名称
为CA证书的主题字段。
- 消息认证码的参考值和秘密值
需要以带外方式从CMPv2服务器上获取消息认证码的参考值和秘密值。

操作步骤

步骤1 配置接口的IP地址及到CA服务器的静态路由。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] interface gigabitethernet 2/0/1
[Router-GigabitEthernet2/0/1] ip address 10.2.0.2 255.255.255.0
[Router-GigabitEthernet2/0/1] quit
[Router] interface gigabitethernet 2/0/2
[Router-GigabitEthernet2/0/2] ip address 10.1.0.2 255.255.255.0
```

```
[Router-GigabitEthernet2/0/2] quit
[Router] ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
```

步骤2 创建RSA密钥对。

创建一个4096位的RSA密钥对rsa_cmp，并设置为可以从设备上导出。

```
[Router] pki rsa local-key-pair create rsa_cmp exportable
Info: The name of the new key-pair will be: rsa_cmp
The size of the public key ranges from 2048 to 4096.
Input the bits in the modules:4096
Generating key-pairs...
.....+++
.....+++
```

步骤3 配置PKI实体，标识申请证书PKI实体的身份信息。

配置PKI实体为用户01。

```
[Router] pki entity user01
[Router-pki-entity-user01] common-name hello
[Router-pki-entity-user01] country cn
[Router-pki-entity-user01] email user@test.abc.com
[Router-pki-entity-user01] fqdn test.abc.com
[Router-pki-entity-user01] ip-address 10.2.0.2
[Router-pki-entity-user01] state jiangsu
[Router-pki-entity-user01] organization
[Router-pki-entity-user01] organization-unit info
[Router-pki-entity-user01] quit
```

步骤4 创建PKI域。

```
[Router] pki realm abc
[Router-pki-realm-abc] quit
```

步骤5 配置CMP会话。

创建CMP会话cmp。

```
[Router] pki cmp session cmp
```

指定CMP会话引用的PKI实体名称。

```
[Router-pki-cmp-session-cmp] cmp-request entity user01
```

配置CA的名称，举例中假设为“C=cn,ST=beijing,L=SD,O=BB,OU=BB,CN=BB”。

说明

配置的CA名称中各个字段的顺序必须要和实际CA证书中的顺序保持一致，否则服务器端会认为是错误的。

```
[Router-pki-cmp-session-cmp] cmp-request ca-name "C=cn,ST=beijing,L=SD,O=BB,OU=BB,CN=BB"
```

配置申请证书的URL。

```
[Router-pki-cmp-session-cmp] cmp-request server url http://10.3.0.1:8080
```

指定申请证书时使用的RSA密钥对，并设置为证书自动更新时同时更新RSA密钥对。

```
[Router-pki-cmp-session-cmp] cmp-request rsa local-key-pair rsa_cmp regenerate
```

指定CMP服务器证书所属的PKI域，并设置CMP服务器证书所属的域名称为abc。

```
[Router-pki-cmp-session-cmp] cmp-request realm abc
```

首次申请证书时，使用消息认证码认证。配置消息认证码的参考值和秘密值，举例中假设分别为“1234”和“YsHsjx_202206”。

```
[Router-pki-cmp-session-cmp] cmp-request message-authentication-code 1234 YsHsjx_202206
[Router-pki-cmp-session-cmp] quit
```

```
[Router] pki cmp initial-request session cmp
[Router]
Info: Initializing configuration.
Info: Creating initial request packet.
Info: Connecting to CMPv2 server.
Info: Sending initial request packet.
Info: Waiting for initial response packet.
Info: Creating confirm packet.
Info: Connecting to CMPv2 server.
Info: Sending confirm packet.
Info: Waiting for confirm packet from server.
Info: CMPv2 operation finish.
```

获取到的CA、本地证书将会分别被命名为cmp_ca1.cer和cmp_ir.cer保存在设备存储介质中。

步骤6 安装证书。

导入CA证书到PKI域。

```
[Router] pki import-certificate ca realm abc pem filename cmp_ca1.cer
The CA's Subject is /C=cn/ST=beijing/L=SD/O=BB/OU=BB/CN=BB
The CA's fingerprint is:
MD5 fingerprint:3AC7 54FD E272 09BE 9008 84EE D1FC 118E
SHA1 fingerprint:492A 8E0B BED2 BE10 C097 9039 99FE F7E1 9AA5 B658
Is the fingerprint correct?(Y/N):y
Info: Succeeded in importing file.
```

导入本地证书到PKI域。

```
[Router] pki import-certificate local realm abc pem filename cmp_ir.cer
Info: Succeeded in importing file.
```

步骤7 配置证书自动更新功能。

配置设备用于证明自己身份的证书，也是待更新的证书cmp_ir.cer。

```
[Router] pki cmp session cmp
[Router-pki-cmp-session-cmp] cmp-request authentication-cert cmp_ir.cer
```

开启证书自动更新的功能。

```
[Router-pki-cmp-session-cmp] certificate auto-update enable
```

配置当前系统时间超过证书有效期的60%时开始更新证书。

```
[Router-pki-cmp-session-cmp] certificate update expire-time 60
[Router-pki-cmp-session-cmp] quit
```

步骤8 验证配置结果。

1. 证书申请成功后，可执行命令**display pki certificate**查看已经导入内存的本地证书的内容。

```
[Router] display pki certificate filename cmp_ir.cer
The x509_obj type is Cert:
Certificate:
Data:
  Version: 3 (0x2)
  Serial Number: 1144733510 (0x443b3f46)
  Signature Algorithm: sha1WithRSAEncryption
  Issuer: C=cn, ST=beijing, L=SD, O=BB, OU=BB, CN=BB
  Validity
    Not Before: Jun 12 09:33:10 2012 GMT
    Not After : Aug 13 02:38:27 2016 GMT
  Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
  Subject Public Key Info:
    Public Key Algorithm: rsaEncryption
    Public-Key: (4096 bit)
    Modulus:
      00:d3:12:fe:57:48:c6:a5:10:12:e9:2f:f9:2a:ff:
      7b:2a:d8:45:69:11:c4:85:30:c4:9a:4d:0f:ad:58:
```

```
e7:56:cd:5c:f0:18:e1:c3:6d:44:c2:c3:5e:64:22:
d1:28:c9:c3:37:3c:34:ed:28:04:7f:62:9e:8b:94:
af:bc:72:de:f6:72:7f:e4:d8:45:31:fd:f9:ac:ce:
5a:b9:c7:1b:23:53:00:28:a6:3b:f5:61:69:5d:ab:
67:cb:bb:e8:96:2f:ce:ab:2c:6b:91:5b:26:91:86:
8f:80:a9:b0:66:c1:16:3d:31:55:a2:d4:b5:5a:af:
85:88:6e:99:f8:f8:53:58:77:26:91:ed:0e:94:ad:
c5:8d:53:67:67:55:08:8d:90:38:e0:5e:96:37:b9:
64:0e:36:e7:cf:9a:d2:77:e4:b0:24:05:a6:eb:03:
6e:ff:f7:ab:be:93:9e:8c:66:7d:31:66:be:6d:c8:
f3:17:9d:86:19:88:21:2d:d9:69:86:5f:b2:55:a4:
db:bc:d7:d0:6b:ac:66:ac:e4:63:9c:66:79:9c:42:
5c:83:b8:9e:4b:6e:67:85:a2:47:19:f1:5c:c0:3c:
c9:a3:47:02:a8:53:69:59:9e:d9:c7:5e:90:83:8d:
ac:cd:21:3c:d5:31:39:49:84:e6:f8:f4:e0:44:dd:
5d:7b
Exponent: 65537 (0x10001)
X509v3 extensions:
  X509v3 Subject Alternative Name:
    IP Address:10.2.0.2, DNS:test.abc.com, email:user@test.abc.com
Signature Algorithm: sha1WithRSAEncryption
53:d5:79:31:7b:40:52:aa:ec:a9:35:ed:07:62:32:c4:ce:22:
d3:37:0e:83:0c:4c:fa:61:dd:8c:db:a8:d3:fd:6a:ca:0e:3c:
91:2c:91:ab:92:31:34:b5:87:1e:30:a4:ff:94:9c:d2:71:3c:
6b:1f:4f:be:a7:20:f2:e1:c2:ad:71:8b:c2:79:0f:50:1f:3c:
f9:87:df:1d:ee:3d:38:8c:f3:30:b7:3b:00:9b:72:38:b0:68:
e1:c0:08:f4:02:91:81:a8:fa:51:9e:53:0d:03:b3:6b:0e:e2:
62:80:ef:2a:a0:cb:9b:9b:91:21:7c:df:fe:6a:38:cc:03:36:
9c:fc

Pki realm name: abc
Certificate file name: cmp_ir.cer
Certificate peer name: -
```

2. 证书申请成功后，可执行命令**display pki certificate**查看已经导入内存的CA证书的内容。

```
[Router] display pki certificate filename cmp_ca1.cer
The x509 object type is certificate:
Certificate:
Data:
  Version: 3 (0x2)
  Serial Number: 2 (0x2)
  Signature Algorithm: sha1WithRSAEncryption
  Issuer: C=cn, ST=beijing, L=SD, O=BB, OU=BB, CN=BB
  Validity
    Not Before: Aug 15 02:38:27 2011 GMT
    Not After : Aug 13 02:38:27 2016 GMT
  Subject: C=cn, ST=beijing, L=SD, O=BB, OU=BB, CN=BB
  Subject Public Key Info:
    Public Key Algorithm: rsaEncryption
    Public-Key: (1024 bit)
    Modulus:
      00:b7:3e:65:7f:3b:3c:18:b8:87:34:39:76:3c:87:
      39:f7:a9:b3:35:9b:e0:e0:5b:c7:4f:3c:bb:fa:dd:
      da:93:0b:55:6e:eb:ba:52:c8:86:d1:cf:14:1e:1c:
      35:c6:53:68:f3:51:e7:2c:d4:b8:fa:0f:b3:04:ef:
      3f:a0:b3:4d:78:c1:26:88:26:15:41:3d:14:7f:67:
      3e:2f:35:32:ce:c7:73:73:43:5c:12:d3:0f:a0:ec:
      96:ae:55:61:27:32:39:a4:f8:32:a1:68:50:e6:3d:
      2b:39:6d:42:e8:09:5d:4f:98:46:6e:fc:80:87:0e:
      36:ca:09:7a:ca:2f:dd:ad:d3
    Exponent: 65537 (0x10001)
  X509v3 extensions:
    X509v3 Basic Constraints: critical
      CA:TRUE
    X509v3 Subject Key Identifier:
      4F:67:F4:CB:F4:C3:F7:61:2C:BD:FF:1D:D1:29:FD:39:28:9F:3B:8B
    X509v3 Key Usage:
      Certificate Sign, CRL Sign
```

```
Netscape Cert Type:
  SSL CA, S/MIME CA, Object Signing CA
Netscape Comment:
  xca certificate
Signature Algorithm: sha1WithRSAEncryption
75:43:24:eb:db:ee:7d:05:30:88:b8:1b:d5:32:ca:51:49:74:
04:94:fe:d0:31:29:6f:72:c7:4a:86:ac:2a:4c:45:24:9d:3c:
b4:30:b5:d1:43:88:29:f7:b4:88:b8:37:dc:dd:f4:fa:42:34:
1c:e6:a5:bc:bb:0b:37:ef:db:8c:b2:b0:bd:97:7f:15:ae:6c:
71:1b:ff:f1:90:13:74:a4:1f:7c:f7:4e:80:5b:42:aa:6b:22:
2a:cf:04:48:29:20:c0:b2:95:38:11:06:be:76:f0:cb:8d:4a:
c6:1a:50:af:31:81:58:ac:14:fe:89:f2:e0:bb:95:3c:94:d0:
54:96
```

```
Pki realm name: abc
Certificate file name: cmp_ca1.cer
Certificate peer name: -
```

3. 配置证书自动更新功能后，当系统检测到时间已经超过了配置的当前证书有效期的60%之后，就会向CMPv2服务器发起证书的更新请求。

由于配置命令**cmp-request rsa local-key-pair**时选择了**regenerate**参数，更新时系统会生成新的RSA密钥对去申请新证书，申请下来的新证书会同时替换设备存储介质中的证书文件和内存中对应的证书。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
pki entity user01
  country CN
  state jiangsu
  organization
  organization-unit info
  common-name hello
  fqdn user@test.abc.com
  ip-address 10.2.0.2
  email user@user@test.abc.com
#
pki realm abc
#
interface GigabitEthernet2/0/1
  ip address 10.2.0.2 255.255.255.0
interface GigabitEthernet2/0/2
  ip address 10.1.0.2 255.255.255.0
#
pki cmp session cmp
  cmp-request ca-name "C=cn,ST=beijing,L=SD,O=BB,OU=BB,CN=BB"
  cmp-request authentication-cert cmp_ir.cer
  cmp-request entity user01
  cmp-request server url http://10.3.0.1:8080
  cmp-request rsa local-key-pair rsa_cmp regenerate
  cmp-request realm abc
  cmp-request message-authentication-code 1234 %^%#ZodFBGH[^BkU2(~>[NRBv]#b>se|@I7""A,IIG_B%^%#
  certificate auto-update enable
  certificate update expire-time 60
#
ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
#
return
```

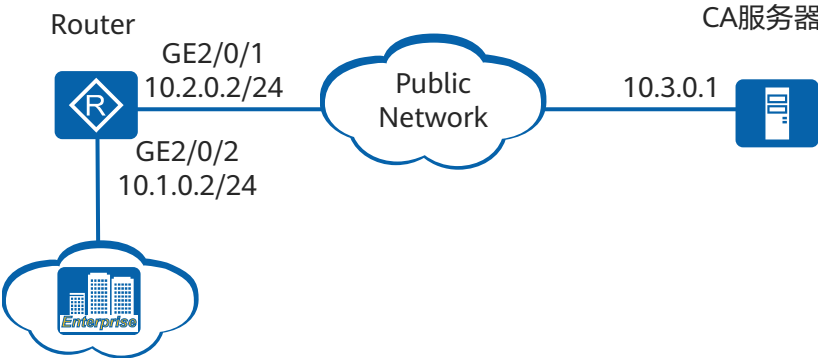

16.9.3 配置为 PKI 实体离线申请本地证书示例

组网需求

如图16-13所示，某企业在网络边界处部署了Router作为出口网关，Router向公网上的CA服务器申请本地证书。

用户无法通过SCEP协议在线向CA申请本地证书时，可以通过带外方式为PKI实体离线申请本地证书。

图 16-13 配置为 PKI 实体离线申请本地证书组网图



说明

本举例只列出了申请证书时Router侧的相关配置，CA服务器的部署和配置请参见相关产品手册。这里的CA服务器以Windows Server 2008自带的“证书服务”，并安装了SCEP插件为例进行说明。

配置思路

采用如下思路配置为PKI实体离线申请本地证书：

1. 创建RSA密钥对，实现申请本地证书时携带公钥。
2. 配置PKI实体，实现申请本地证书时携带PKI实体信息用来标识PKI实体的身份。
3. 配置为PKI实体离线申请本地证书，生成本地证书请求文件。
4. 通过带外方式发送本地证书请求文件来申请本地证书，并通过带外方式下载本地证书。
5. 安装本地证书，使得设备可以使用证书来保护通信。

操作步骤

步骤1 创建RSA密钥对。

创建一个2048位的RSA密钥对rsa，并设置为可以从设备上导出。

```
[Router] pki rsa local-key-pair create rsakey exportable
Info: The name of the new key-pair will be: rsakey
The size of the public key ranges from 2048 to 4096.
Input the bits in the modules:2048
Generating key-pairs...      .....+++
.....+++
```

 说明

当需要备份RSA密钥对或者RSA密钥对给其他设备使用时，可以执行命令**pki export rsa-key-pair key-name [and-certificate certificate-name] { pem file-name [3des | aes | des] | pkcs12 file-name }** password password，将RSA密钥对导出到设备的存储介质中，同时支持导出与其关联的证书。然后用户可以通过SFTP获取RSA密钥对。

步骤2 配置PKI实体，标识申请证书PKI实体的身份信息。

配置PKI实体为user01。

```
[Router] pki entity user01
[Router-pki-entity-user01] common-name test.abc.com
[Router-pki-entity-user01] quit
```

 说明

common-name需要配置为域名或者IP地址。

步骤3 配置为PKI实体离线申请本地证书。

```
[Router] pki realm abc
[Router-pki-realm-abc] entity user01
[Router-pki-realm-abc] rsa local-key-pair rsakey
[Router-pki-realm-abc] quit
[Router] pki enroll-certificate realm abc pkcs10 filename cer_req
Info: Creating certificate request file...
Info: Create certificate request file successfully.
```

已完成配置后，可执行命令**display pki cert-req**查看证书请求文件的内容。

```
[Router] display pki cert-req filename cer_req
Certificate Request:
Data:
  Version: 0 (0x0)
  Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
  Subject Public Key Info:
    Public Key Algorithm: rsaEncryption
    Public-Key: (2048 bit)
    Modulus:
      00:a2:db:e3:30:17:8e:f6:2d:2e:64:15:46:51:ad:
      70:86:dd:32:c4:bb:6b:58:3a:8c:5f:a0:06:a1:e1:
      56:2e:a4:eb:7e:12:06:05:04:28:b2:6d:64:7a:9c:
      4f:85:24:c1:aa:b8:99:dc:e9:bb:c4:1e:e2:9d:a0:
      18:51:1f:ad:b5:2f:60:18:06:8b:c1:cc:6f:32:58:
      f2:21:2c:16:e8:29:c2:a8:c5:aa:9d:6c:1e:ca:14:
      fc:7a:e9:bc:07:91:ce:ed:a0:c0:52:d9:0c:e9:ba:
      9b:64:43:e0:9a:3f:c5:d1:2c:86:36:96:6b:4b:4f:
      d4:df:05:d0:4b:41:2c:ec:0a:d7:0e:45:83:ed:cd:
      07:78:40:ed:d5:3d:7f:fe:0f:08:90:04:2e:ac:e5:
      42:b9:81:ea:ec:77:e2:cc:04:6e:e4:63:9f:69:ed:
      60:06:5e:c7:e8:bf:30:57:6a:5d:e0:46:68:d3:ee:
      b0:da:47:24:e3:b6:a5:f3:20:d8:5a:75:92:70:c2:
      a9:a6:97:07:07:0d:1c:94:9a:03:6f:f7:8c:db:6f:
      b7:06:de:51:50:9e:71:fd:86:f3:b5:c9:99:05:bf:
      f1:10:20:28:d3:a6:29:3d:e0:f4:a7:ba:1e:27:85:
      a9:66:fc:a9:90:49:f0:35:f7:d9:6d:06:a2:43:3f:
      18:87
    Exponent: 65537 (0x10001)
  Attributes:
    Requested Extensions:
      X509v3 Subject Alternative Name:
        IP Address:10.2.0.2, DNS:test.abc.com, email:user@test.abc.com
  Signature Algorithm: sha256WithRSAEncryption
  0e:0a:a5:b7:d5:54:11:10:c4:ea:ff:77:da:f9:24:4b:a9:98:
  a1:75:36:08:10:59:60:fa:1a:30:70:2c:b7:f6:5f:5e:31:b7:
  55:a5:7a:26:e5:af:4a:cd:83:c5:f3:90:f3:b9:d5:f9:0a:6d:
  6e:8f:25:b4:ed:95:9c:75:a5:d7:b6:25:fc:8d:39:89:fb:af:
  37:fc:01:7b:09:07:9c:96:7c:fa:28:6d:e2:11:49:a7:95:94:
```

```
ed:26:5b:ca:f8:98:b0:e7:64:7e:dd:2d:75:ff:89:03:b7:0a:
92:53:25:d4:a1:23:b9:5c:eb:5b:29:1d:8a:92:8f:36:68:7b:
77:32:bc:48:92:48:84:fa:87:5a:d7:2e:3e:be:d5:6b:e4:df:
b1:f2:02:35:91:6a:eb:cd:fc:5a:ea:37:85:6c:12:74:5f:a5:
5c:c0:05:09:cd:34:59:0d:c6:c8:75:ca:1c:18:d6:48:e5:4b:
e7:8e:e3:ff:25:99:0f:2e:a8:b4:c5:8e:4d:8f:dd:64:c5:1f:
61:3c:58:21:4f:d5:35:ba:c8:8e:5f:76:41:9f:27:41:0a:94:
59:2c:59:25:2d:de:60:5c:92:07:ac:8a:a5:7a:ba:75:af:2c:
82:5f:bb:55:a8:48:49:54:0f:99:54:af:8d:12:4d:4b:7d:8b:
95:28:ce:dc
```

步骤4 通过Web、磁盘、电子邮件等带外方式将证书申请文件发送给CA服务器，向CA服务器申请本地证书。

本地证书注册成功后，可以通过带外方式下载本地证书abc_local.cer。下载后，可以通过文件传输协议导入到设备的存储介质中。

步骤5 安装本地证书。

导入CA证书到PKI域。

```
[Router] pki import-certificate ca realm abc pem filename ca.cer
The CA's Subject is /C=cn/ST=beijing/L=SD/O=BB/OU=BB/CN=BB
The CA's fingerprint is:
MD5 fingerprint:3AC7 54FD E272 09BE 9008 84EE D1FC 118E
SHA1 fingerprint:492A 8E0B BED2 BE10 C097 9039 99FE F7E1 9AA5 B658
Is the fingerprint correct?(Y/N):y
Info: Succeeded in importing file.
```

导入本地证书到PKI域。

```
[Router] pki import-certificate local realm abc pem filename abc_local.cer
Info: Succeeded in importing file.
```

安装本地证书后，设备就可以使用证书来保护通信。

步骤6 验证配置结果。

执行命令**display pki certificate local**查看已经导入内存的本地证书的内容。

```
[Router] display pki certificate local realm abc
The x509 object type is certificate:
Certificate:
  Data:
    Version: 3 (0x2)
    Serial Number:
      48:65:aa:2a:00:00:00:00:3f:c6
    Signature Algorithm: sha1WithRSAEncryption
    Issuer: CN=ca_root
    Validity
      Not Before: Dec 21 11:46:10 2015 GMT
      Not After : Dec 21 11:56:10 2016 GMT
    Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
    Subject Public Key Info:
      Public Key Algorithm: rsaEncryption
      Public-Key: (2048 bit)
      Modulus:
        00:94:6f:49:bd:6a:f3:d5:07:ee:10:ee:4f:d3:06:
        80:59:15:cb:a8:0a:b2:ba:c2:db:52:ec:e9:d1:a7:
        72:de:ac:35:df:bb:e0:72:62:08:3e:c5:54:c1:ba:
        4a:bb:1b:a9:d9:dc:e4:b6:4d:ca:b3:54:90:b6:8e:
        15:a3:6e:2d:b2:9e:9e:7a:33:b0:56:3f:ec:bc:67:
        1c:4c:59:c6:67:0f:a7:03:52:44:8c:53:72:42:bd:
        6e:0c:90:5b:88:9b:2c:95:f7:b8:89:d1:c2:37:3e:
        93:78:fa:cb:2c:20:22:5f:e5:9c:61:23:7b:c0:e9:
        fe:b7:e6:9c:a1:49:0b:99:ef:16:23:e9:44:40:6d:
        94:79:20:58:d7:e1:51:a1:a6:4b:67:44:f7:07:71:
        54:93:4e:32:ff:98:b4:2b:fa:5d:b2:3c:5b:df:3e:
        23:b2:8a:1a:75:7e:8f:82:58:66:be:b3:3c:4a:1c:
        2c:64:d0:3f:47:13:d0:5a:29:94:e2:97:dc:f2:d1:
```

```
06:c9:7e:54:b3:42:2e:15:b8:40:f3:94:d3:76:a1:
91:66:dd:40:29:c3:69:70:6d:5a:b7:6b:91:87:e8:
bb:cb:a5:7e:ec:a5:31:11:f3:04:ab:1a:ef:10:e6:
f1:bd:d9:76:42:6c:2e:bf:d9:91:39:1d:08:d7:b4:
18:53
Exponent: 65537 (0x10001)
X509v3 extensions:
X509v3 Subject Alternative Name:
  IP Address:10.2.0.2, DNS:test.abc.com, email:user@test.abc.com
X509v3 Subject Key Identifier:
  15:D1:F6:24:EB:6B:C0:26:19:58:88:91:8B:60:42:CE:BA:D5:4D:F3
X509v3 Authority Key Identifier:
  keyid:B8:63:72:A4:5E:19:F3:B1:1D:71:E1:37:26:E1:46:39:01:B6:82:C
5

X509v3 CRL Distribution Points:

Full Name:
  URI:file:///\\vasp-e6000-127.china..com\CertEnroll\ca_roo
t.crl

  URI:http://10.3.0.1:8080/certenroll/ca_root.crl

Authority Information Access:
  CA Issuers - URI:http://vasp-e6000-127.china..com/CertEnro
ll/vasp-e6000-127.china..com_ca_root.crt
  OCSP - URI:file:///\\vasp-e6000-127.china..com\CertEnroll\vasp-
e6000-127.china..com_ca_root.crt

1.3.6.1.4.1.311.20.2:
.O.I.P.S.E.C.I.n.t.e.r.m.e.d.i.a.t.e.O.f.f.l.i.n.e
Signature Algorithm: sha1WithRSAEncryption
d2:be:a8:52:6b:03:ce:89:f1:5b:49:d4:eb:2b:9f:fd:59:17:
d4:3c:f1:db:4f:1b:d1:12:ac:bf:ae:59:b4:13:1b:8a:20:d0:
52:6a:f8:a6:03:a6:72:06:41:d2:a7:7d:3f:51:64:9b:84:64:
cf:ec:4c:23:0a:f1:57:41:53:eb:f6:3a:44:92:f3:ec:bd:09:
75:db:02:42:ab:89:fa:c4:cd:cb:09:bf:83:1d:de:d5:4b:68:
8a:a6:5f:7a:e8:b3:34:d3:e8:ec:24:37:2b:bd:3d:09:ed:88:
d8:ed:a7:f8:66:aa:6f:b0:fe:44:92:d4:c9:29:21:1c:b3:7a:
65:51:32:50:5a:90:fa:ae:e1:19:5f:c8:63:8d:a8:e7:c6:89:
2e:6d:c8:5b:2c:0c:cd:41:48:bd:79:74:0e:b8:2f:48:69:df:
02:89:bb:b3:59:91:7f:6b:46:29:7e:22:05:8c:bb:6a:7e:f3:
11:5a:5f:fb:65:51:7d:35:ff:49:9e:ec:d1:2d:7e:73:e5:99:
c6:41:84:0c:50:11:ed:97:ed:15:de:11:22:73:a1:78:11:2e:
34:e6:f5:de:66:0c:ba:d5:32:af:b8:54:26:4f:5b:9e:89:89:
2a:3f:b8:96:27:00:c3:08:3a:e9:e8:a6:ce:4b:5a:e3:97:9e:
6b:dd:f0:72

Pki realm name: abc
Certificate file name: abc_local.cer
Certificate peer name: -
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
pki entity user01
  common-name test.abc.com
#
pki realm abc
  entity user01
  rsa local-key-pair rsakey
#
interface GigabitEthernet2/0/1
  ip address 10.2.0.2 255.255.255.0
```

```
interface GigabitEthernet2/0/2
ip address 10.1.0.2 255.255.255.0
#
ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
#
return
```

16.10 PKI 常见配置错误

16.10.1 获取 CA 证书失败

故障现象

- 通过手工方式获取CA证书，查看设备存储介质中没有下载到CA证书，其失败的原因因为通过HTTP或LDAP方式下载CA证书时配置的不正确。
- 通过SCEP协议获取CA证书，查看设备存储介质中没有下载到CA证书，其失败的原因如下：
 - 获取CA证书的命令未配置。
 - 信任的CA名称配置的不正确或未配置。
 - 证书注册服务器的URL配置的不正确或未配置。
 - 指定的PKI实体未配置。
 - 指纹信息配置的不正确或未配置。
 - 使用的RSA密钥对未配置。
 - TCP连接使用的源接口配置的不正确。

操作步骤

- 通过手工方式获取CA证书

检查HTTP或LDAP方式下载CA证书的配置是否正确。如果不正确，请修改相应的内容。详情请参见命令**pki http**或**pki ldap**。
- 通过SCEP协议获取CA证书
 - 检查在系统视图下是否已执行命令**pki get-certificate**申请CA证书。

如果没有，请执行本命令。当申请CA证书相关配置不全时，会提示您配置相应的内容。
 - 检查PKI域下配置的申请CA证书的相关配置是否正确。

可以在任意视图下执行命令**display pki realm**或者在PKI域下执行**display this**查看。

如下所示，这里例举申请CA证书所需的配置。

```
pki realm test
ca id ca_server //配置PKI域信任的CA
enrollment-url http://10.13.14.15:8080/certsrv/mscep/mscep.dll //配置证书注册服务器的URL
entity zzz //指定使用的PKI实体
fingerprint sha1 7a34d94624b1c1bcbf6d763c4a67035d5b578eaf //配置对CA证书进行认证时使用的CA证书指纹，从CA服务器上获取
rsa local-key-pair 8 //指定使用的RSA密钥对
source interface Ethernet0/0/2 //指定TCP连接使用的源接口（确保该接口为三层接口，且接口下已经配置了IP地址），缺省情况下设备使用出接口作为TCP连接的源接口
```

如果相关配置不正确，请修改相应的内容。详情请参见[16.7.2.1 配置通过SCEP协议为PKI实体申请和更新本地证书](#)。

----结束

16.10.2 获取本地证书失败

故障现象

- 通过手工方式离线获取本地证书，查看设备存储介质中没有下载到本地证书，其失败的原因如下：
 - 指定的PKI实体配置的不正确。
 - 挑战密码配置的不正确或未配置。
 - 通过HTTP或LDAP方式下载本地证书时配置的不正确。
- 通过SCEP或CMPv2协议获取本地证书，查看设备存储介质中没有下载到本地证书，其失败的原因如下：
 - 执行获取操作之前PKI域中没有CA证书。
 - 指定的PKI实体配置的不正确或未配置。
 - 信任的CA名称配置的不正确或未配置。
 - 证书注册服务器的URL配置的不正确或未配置。
 - 使用的RSA密钥对未配置。
 - TCP连接使用的源接口配置的不正确。
 - 签名证书注册请求消息使用的摘要算法配置的不正确。
 - 挑战密码配置的不正确或未配置。
 - 消息认证码的参考值和秘密值配置的不正确或未配置。
 - 用于证明身份的证书配置不正确。

操作步骤

- 通过手工方式获取本地证书
 - 检查配置的PKI实体配置是否正确。

在PKI域下指定的PKI实体，可以执行命令**display pki entity**查看配置的PKI实体信息。

如果某些内容配置错误，例如PKI实体所属的国家代码配置错误，请修改相应的内容。详情请参见[16.7.1.1 配置PKI实体信息](#)。
 - 检查挑战密码配置是否正确。

请先确定CA服务器是否要验证挑战密码，如果是，请配置CA服务器的挑战密码，两者要一致。详情请参见命令**pki enroll-certificate**。
 - 检查HTTP或LDAP方式下载本地证书的配置是否正确。

如果不正确，请修改相应的内容。详情请参见命令**pki http**或**pki ldap**。
- 通过SCEP或CMPv2协议获取本地证书
 - 检查CA证书是否已导入设备的内存中。

可以执行命令**display pki certificate**查看设备内存中的CA证书。

如果没有请获取CA证书并执行命令**pki import-certificate**将CA证书导入设备的内存中。

- b. 检查配置的PKI实体配置是否正确。

在PKI域下指定的PKI实体，可以执行命令**display pki entity**查看配置的PKI实体信息。

如果某些内容配置错误，例如PKI实体所属的国家代码配置错误，请修改相应的内容。详情请参见[16.7.1.1 配置PKI实体信息](#)。

- c. 检查PKI域或者CMP会话下配置的申请CA证书的相关配置是否正确。

■ PKI域下

可以在任意视图下执行命令**display pki realm**或者在PKI域下执行命令**display this**查看。

如下所示，这里例举申请本地证书所需的配置。

```
pki realm test
ca id ca_server //配置PKI域信任的CA
enrollment-url http://10.13.14.15:8080/certsrv/mscep/mscep.dll //配置证书注册服务器的URL
entity zzz //指定使用的PKI实体
rsa local-key-pair 8 //指定使用的RSA密钥对
password cipher %^%#\1HN-bn(k;\O85OAtYF3(M4%^%# //配置SCEP证书申请时使用的挑战密码，与CA服务器一致
source interface gigabitethernet 1/0/2 //指定TCP连接使用的源接口（确保该接口为三层接口，且接口下已经配置了IP地址），缺省情况下设备使用出接口作为TCP连接的源接口
enrollment-request signature message-digest-method sha1 //配置签名证书注册请求消息使用的摘要算法，与CA服务器一致
```

如果相关配置不正确，请修改相应的内容。详情请参见[16.7.2.1 配置通过SCEP协议为PKI实体申请和更新本地证书](#)。

■ CMP会话下

可以在CMP会话下执行命令**display this**查看。

如下所示，这里例举申请CA证书所需的配置。

```
pki cmp session cmp
cmp-request ca-name "C=cn,ST=beijing,L=SD,O=BB,OU=BB,CN=BB" //配置CA的名称，CA名称中各个字段的顺序必须要和实际CA证书中的顺序保持一致
cmp-request authentication-cert local.cer //配置CMPv2请求中用于证明身份的证书，用于更新证书或为其他设备申请证书等
cmp-request entity user01 //指定使用的PKI实体
cmp-request server url http://10.3.0.1:8080 //配置CMPv2服务器的URL
cmp-request rsa local-key-pair rsa regenerate //指定使用的RSA密钥对
cmp-request message-authentication-code 1234 %^%#ZodFBGH[^BkU2(->[NRBv|#b>se|@I7"A,IlG_B%^%# //配置消息认证码的参考值和秘密值，与CA服务器一致
```

如果相关配置不正确，请修改相应的内容。详情请参见[16.7.2.2 配置通过CMPv2协议为PKI实体申请和更新本地证书](#)。

----结束

16.11 PKI FAQ

16.11.1 CA 证书、本地证书和自签名证书的区别？

CA证书、本地证书和自签名证书的区别如[表16-5](#)所示。

表 16-5 证书类型

类型	描述	说明
自签名证书	自签名证书又称为根证书，是自己颁发给自己的证书，即证书中的颁发者和主体名相同。	申请者无法向CA申请本地证书时，可以通过设备生成自签名证书，可以实现简单证书颁发功能。 设备不支持对其生成的自签名证书进行生命周期管理（如证书更新、证书撤销等），为了确保设备和证书的安全，建议用户替换为自己的本地证书。
CA证书	CA自身的证书。如果PKI系统中没有多层级CA，CA证书就是自签名证书；如果有多层级CA，则会形成一个CA层次结构，最上层的CA是根CA，它拥有一个CA“自签名”的证书。	申请者通过验证CA的数字签名从而信任CA，任何申请者都可以得到CA的证书（含公钥），用以验证它所颁发的本地证书。
本地证书	CA颁发给申请者的证书。	-
设备本地证书	设备根据CA证书给自己颁发的证书，证书中的颁发者名称是CA服务器的名称。	申请者无法向CA申请本地证书时，可以通过设备生成设备本地证书，可以实现简单证书颁发功能。

16.11.2 证书支持哪几种格式？

设备支持三种文件格式保存证书，如下表所示。

表 16-6 证书格式

格式	描述	说明
PKCS#12	以二进制格式保存证书，可以包含私钥，也可以不包含私钥。常用的后缀有：.P12和.PFX。	对于证书后缀为.CER或.CRT，可以用记事本打开证书，查看证书内容来区分证书格式。 - 如果有类似 " -----BEGIN CERTIFICATE----- " 和 " -----END CERTIFICATE----- " 的头尾标记，则证书格式为PEM。 - 如果是乱码，则证书格式为DER。
DER	以二进制格式保存证书，不包含私钥。常用的后缀有：.DER、.CER和.CRT。	

格式	描述	说明
PEM	以ASCII码格式保存证书，可以包含私钥，也可以不包含私钥。常用的后缀有：.PEM、.CER和.CRT。	

16.11.3 如何手工导入证书和 RSA 密钥对？

说明

设备支持三种文件格式保存证书：PKCS#12、DER、PEM。详细描述参考[16.11.2 证书支持哪几种格式？](#)。

用户通过设备生成证书请求文件（RSA密钥对已经在设备上生成），并将证书请求文件提供给证书颁发机构（CA），CA只颁发本地证书。用户只需将CA提供的CA和本地证书导入设备内存中，无需导入RSA密钥对。

手工替换CA和本地证书时，请先确保证CA和本地证书未被业务使用，然后再执行命令**pki delete-certificate**删除CA和本地证书。例如删除本地证书：

```
[Huawei] pki delete-certificate local realm abc
```

手工导入证书和RSA密钥对的步骤如下所示：

1. 用户已通过Web、磁盘、电子邮件等带外方式将申请证书信息发送给CA申请本地证书。
2. 下载CA提供的CA证书、本地证书和RSA密钥对文件，并通过TFTP等方式上传至设备的存储介质中。

一般情况下，DER和PEM格式的证书和密钥对文件是分开的，PKCS#12格式的证书和密钥对在同一个文件中。

3. 导入CA证书，如果有多个CA证书，则需导入全部CA证书。

例如，获取到的CA证书文件名为rootca.pem。

```
<Huawei> system-view
[Huawei] pki realm abc
[Huawei-pki-realm-abc] quit
[Huawei] pki import-certificate ca realm abc pem filename rootca.pem
```

导入成功后，查看CA证书的信息。

```
[Huawei] display pki certificate ca realm abc
```

4. 导入本地证书。

例如，获取到的本地证书文件名为localcert.pem。

```
[Huawei] pki import-certificate local realm abc pem filename localcert.pem
```

导入成功后，查看本地证书的信息。

```
[Huawei] display pki certificate local realm abc
```

5. 导入RSA密钥对。对于PEM和PKCS#12格式的文件还需要CA提供的RSA密钥对相应的密码。

例如，获取到的RSA密钥对文件名为local_privatekey.pem，密码为YsHsjx_202206。

```
[Huawei] pki import rsa-key-pair abc pem local_privatekey.pem password YsHsjx_202206
```

导入成功后，查看RSA密钥对的信息。

```
[Huawei] display pki rsa local-key-pair name abc public
```

6. 检查导入的本地证书和RSA密钥对是否匹配，如果没有找到匹配的密钥对，请检查导入的文件是否正确。

```
[Huawei] pki match-rsa-key certificate-filename localcert.pem
```

Info: The file localcert.pem contains certificates 1.

Info: Certificate 1 from file localcert.pem matches RSA key test.

17 SSL 配置

- [17.1 SSL概述](#)
- [17.2 SSL配置注意事项](#)
- [17.3 SSL缺省配置](#)
- [17.4 配置服务器型SSL策略](#)
- [17.5 配置客户端型SSL策略](#)
- [17.6 维护SSL](#)
- [17.7 SSL配置举例](#)

17.1 SSL 概述

概述

SSL协议是在Internet基础上提供的一种保证私密性的安全协议。它能使客户端与服务器之间的通信不被攻击者窃听，并且始终对服务器进行认证，还可选择对客户端进行认证。目前，SSL协议广泛应用于电子商务、网上银行等领域。SSL具有以下优点：

- 提供较高的安全性保证。SSL利用数据加密、身份验证和消息完整性验证机制，保证网络上数据传输的安全性。
- 支持各种应用层协议。虽然SSL设计的初衷是为了解决万维网安全性问题，但是由于SSL位于应用层和传输层之间，它可以为任何基于TCP可靠连接的应用层协议提供安全性保证。
- 部署简单。目前SSL已经成为网络中用来鉴别网站和网页浏览者身份，在浏览器使用者及Web服务器之间进行加密通信的全球化标准。

SSL从以下几方面提高了设备的安全性：

- 通过SSL协议保证合法客户端可以安全地访问服务器，禁止非法的客户端访问服务器。
- 客户端与服务器之间交互的数据需要经过加密和摘要，加密保证了传输的安全性，摘要保证了数据的完整性，从而实现了设备的安全管理。
- 为设备制定基于证书属性的访问控制策略，对客户端的访问权限进行控制，进一步避免了非法客户对设备进行攻击。

基本概念

- CA（Certificate Authority）

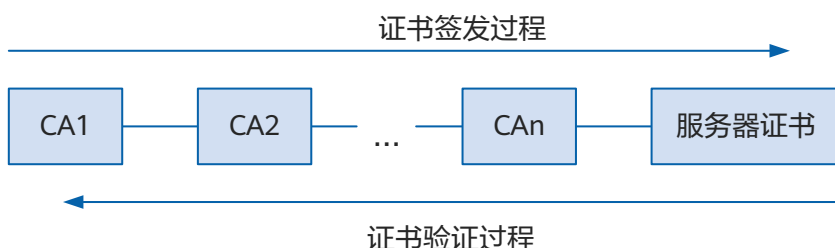
CA是发放、管理、废除数字证书的机构。CA的作用是检查数字证书持有者身份的合法性，并签发数字证书（在证书上签字），以防证书被伪造或篡改，以及对证书和密钥进行管理。国际上被广泛信任的CA，被称之为根CA。根CA可授权其它CA为其下级CA。CA的身份也需要证明，而证明信息在信任证书机构文件中描述。

例如：CA1作为最上级CA也叫根证书，签发下一级CA2证书，CA2又可以给它的下一级CA3签发证书，以此下去，最终由CAn签发服务器的证书。

如果服务器端的证书由CA3签发，则在客户端验证证书的过程从服务器端的证书有效性验证开始。先由CA3证书验证服务器端证书的有效性，如果通过则再由CA2证书验证CA3证书的有效性，最后由最上级CA1证书验证CA2证书的有效性。只有通过最上级CA证书即根证书的验证，服务器证书才会验证成功。

证书签发过程与证书验证过程如图17-1所示。

图 17-1 证书签发过程与证书验证过程示意图



- 数字证书

数字证书实际上是存于计算机上的一个记录，是由CA签发的一个声明，证明证书主体（证书申请者拥有了证书后即成为证书主体）与证书中所包含的公钥的唯一对应关系。数字证书中包括证书申请者的名称及相关信息、申请者的公钥、签发数字证书的CA的数字签名及数字证书的有效期等内容。数字证书的作用使网上通信双方的身份得到了互相验证，提高了通信的可靠性。

用户必须事先获取信息发送者的公钥证书，以便对信息进行解码认证，同时还需要CA发送给发送者的证书，以使用户验证发送者的身份。

- 证书撤销列表CRL（Certificate Revocation List）

CRL由CA发布，它指定了一套证书发布者认为无效的证书。

数字证书的寿命是有限的，但CA可通过证书撤销过程缩短证书的寿命。CRL指定的寿命通常比数字证书指定的寿命要短。由CA撤销数字证书，意味着CA在数字证书正常到期之前撤销允许使用密钥对的有关声明。在撤销证书到期后，CRL中的有关数据被删除，以缩短CRL列表的大小。

任何一个证书被废除以后，证书机构CA就要发布CRL来声明该证书是无效的，并列出所有被废除证书的签发者和序列号、CRL的签发日期、证书被撤销的日期、CRL下次发布时间等信息。

CRL提供了一种检验证书有效性的方式，当终端实体需要验证对端证书合法性时，通常需要检查对端证书的CRL，判断该证书是否被撤销。

协议安全机制

SSL协议提供的安全机制如下：

- 连接的私密性
SSL利用对称加密算法对传输数据进行加密，并利用密钥交换算法—RSA（Rivest Shamir and Adleman，非对称密钥算法的一种）加密传输对称密钥算法中使用的密钥。
- 身份验证机制
基于证书利用数字签名方法对服务器和客户端进行身份验证。SSL服务器和客户端通过公钥基础设施PKI（Public Key Infrastructure）提供的机制从CA获取证书。
- 内容的可靠性
消息传输过程中使用基于密钥的消息验证码MAC（Message Authentication Code）来检验消息的完整性。
MAC算法是将密钥和任意长度的数据转换为固定长度数据的一种算法。
 - 发送端在密钥参与下，利用MAC算法计算出消息的MAC值，并将其加在消息之后发送给接收端。
 - 接收端利用同样的密钥和MAC算法计算出消息的MAC值，并与接收到的MAC值比较。如果二者相同，则报文没有改变。否则，报文在传输过程中被修改，接收端将丢弃该报文。

17.2 SSL 配置注意事项

涉及网元

- SSL服务器
- SSL客户端

License 支持

SSL特性无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

17.3 SSL 缺省配置

SSL的缺省配置如[表17-1](#)所示。

表 17-1 SSL 缺省配置

参数	缺省值
客户端型SSL策略使用的SSL协议版本	TLS1.2
客户端型SSL策略使用的加密套件	rsa_aes_128_cbc_sha、rsa_aes_128_sha256、rsa_aes_256_sha256、rsa_aes128_ccm、rsa_aes128_gcm_sha256、rsa_aes256_ccm、rsa_aes256_gcm_sha384、ecdhe_rsa_aes128_gcm_sha256和ecdhe_rsa_aes256_gcm_sha384
服务器型SSL策略支持的加密套件	rsa_aes_128_cbc_sha、rsa_aes_128_sha256、rsa_aes_256_sha256、rsa_aes128_ccm、rsa_aes128_gcm_sha256、rsa_aes256_ccm、rsa_aes256_gcm_sha384、ecdhe_rsa_aes128_gcm_sha256和ecdhe_rsa_aes256_gcm_sha384
保存会话的最大数目和最大时长	缺省情况下，保存会话的最大时长为3600秒，保存会话的最大数目为16、128或256。

17.4 配置服务器型 SSL 策略

前提条件

PKI域已成功配置。

背景信息

SSL利用数据加密、身份验证和消息完整性验证机制，为基于TCP可靠连接的应用层协议提供安全性保证。应用层协议（如HTTP协议）可以关联服务器型SSL策略，使应用层协议与SSL结合，从而为应用层协议提供安全连接。

图 17-2 Router 作为 SSL 服务器示意图



如图17-2所示，管理员在Router配置服务器型SSL策略后，Router可以作为SSL服务器。在SSL握手过程中，Router使用服务器型SSL策略所设置的SSL参数与SSL客户端之间协商会话参数，并建立会话。

Router作为SSL服务器时，允许SSL客户端对其进行身份验证，但它不具备对SSL客户端进行身份验证的功能。

说明

Router作为SSL服务器时，可以与TLS1.1和TLS1.2版本的SSL客户端通信。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**ssl policy *policy-name* type server**，创建服务器型SSL策略，并进入服务器型SSL策略视图。

步骤3 执行命令**pki-realm *realm-name***，配置服务器型SSL策略所使用的PKI域。

缺省情况下，Router没有配置服务器型SSL策略所使用的PKI域。

说明

作为SSL服务器的Router基于PKI域从认证机构CA获取数字证书，以便SSL客户端可以根据数字证书对Router进行身份验证。

Router也支持自身生成自签名证书，但由于设备不支持对该证书进行生命周期管理（如证书更新、证书撤销等），为了确保设备和证书的安全，建议用户替换为自己的证书。

步骤4 （可选）执行命令**version { *tls1.1* | *tls1.2* } ***，配置服务器型SSL策略使用的SSL协议版本。

缺省情况下，服务器型SSL策略使用的SSL协议版本为TLS1.2。

推荐使用TLS1.2。其他协议版本存在安全风险，V300R021C10及之后版本，在配置时需要输入“y”进行确认。

步骤5 （可选）执行命令**session { *cachesize size* | *timeout time* } ***，配置保存会话的最大数目和最大时长。

缺省情况下，保存会话的最大时长为3600秒，保存会话的最大数目为16、128或256。

步骤6 （可选）执行命令**ciphersuite { *rsa_3des_cbc_sha* | *rsa_aes_128_cbc_sha* | *rsa_aes_128_sha256* | *rsa_aes_256_sha256* | *rsa_aes128_ccm* | *rsa_aes128_gcm_sha256* | *rsa_aes256_ccm* | *rsa_aes256_gcm_sha384* | *ecdhe_rsa_aes128_gcm_sha256* | *ecdhe_rsa_aes256_gcm_sha384* } ***，配置服务器型SSL策略支持的加密套件。

缺省情况下，服务器型SSL策略支持的加密套件为**rsa_aes_128_cbc_sha**、**rsa_aes_128_sha256**、**rsa_aes_256_sha256**、**rsa_aes128_ccm**、**rsa_aes128_gcm_sha256**、**rsa_aes256_ccm**、**rsa_aes256_gcm_sha384**、**ecdhe_rsa_aes128_gcm_sha256**和**ecdhe_rsa_aes256_gcm_sha384**。

说明

缺省情况下，支持的加密套件为**rsa_aes128_gcm_sha256**、**rsa_aes256_gcm_sha384**、**rsa_aes128_ccm**、**rsa_aes256_ccm**、**ecdhe_rsa_aes128_gcm_sha256**和**ecdhe_rsa_aes256_gcm_sha384**。

步骤7 （可选）配置SSL重协商功能。

当设备遇到重协商攻击时，可通过去使能重协商功能来阻止攻击，但去使能重协商功能的同时会造成业务中断。因此也可以在使能SSL连接重协商功能的同时配置SSL连接重协商速率，减轻重协商对设备造成的攻击，尽量保证业务正常运行。以下任务二选一。

- 去使能重协商功能
执行命令**undo renegotiation enable**，去使能SSL连接重协商功能。
缺省情况下，SSL连接重协商功能处于使能状态。
- 配置重协商速率
 - a. 执行命令**quit**，返回系统视图。
 - b. 执行命令**ssl renegotiation-rate rate**，配置SSL连接重协商速率。
缺省情况下，SSL连接重协商速率为1次/秒，用户可基于设备CPU的能力适当调整重协商速率。
此配置对所有SSL策略均生效。

步骤8 （可选）使能记录SSL服务端是否成功接受客户端连接日志的功能

设备作为SSL服务器时，如果用户需要通过日志查看设备是否成功接受客户端的连接，可以使用**ssl log enable**命令打开记录日志功能。如果接受连接成功，设备会记录日志**SSLA/6/SSL_ACCEPT**；如果接受连接失败，设备会记录日志**SSLA/3/SSL_ACCEPT_FAIL**。

1. 执行命令**quit**，返回系统视图。
2. 执行命令**ssl log enable [restrain times]**，打开SSL服务端接受客户端连接记录日志的功能。
缺省情况下，未使能SSL服务端接受客户端连接记录日志的功能。

📖 说明

V300R021C10及之后版本支持此功能。

----结束

检查配置结果

执行命令**display ssl policy [policy-name]**，查看SSL策略的配置信息。

17.5 配置客户端型 SSL 策略

前提条件

PKI域已成功配置。

背景信息

SSL利用数据加密、身份验证和消息完整性验证机制，为基于TCP可靠连接的应用层协议提供安全性保证。应用层协议（如CWMP协议）可以关联客户端型SSL策略，使应用层协议与SSL结合，从而为应用层协议提供安全连接。

图 17-3 Router 作为 SSL 客户端示意图



如图17-3所示，管理员在Router上配置客户端型SSL策略后，Router可以作为SSL客户端。在SSL握手过程中，Router使用客户端型SSL策略所设置的SSL参数与SSL服务器之间协商会话参数，并建立会话。

Router作为SSL客户端时，不允许SSL服务器对其进行身份验证，但可以选择对SSL服务器进行身份验证。为了保证通信安全，当Router作为SSL客户端时，请使能基于证书的SSL服务器身份验证。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**ssl policy *policy-name* type client**，创建客户端型SSL策略，并进入客户端型SSL策略视图。

步骤3 执行命令**server-verify enable**，使能基于证书的SSL服务器身份验证。

缺省情况下，使能基于证书的SSL服务器身份验证。

步骤4 执行命令**pki-realm *realm-name***，配置客户端型SSL策略所使用的PKI域。

缺省情况下，Router没有配置客户端型SSL策略所使用的PKI域。

说明

作为SSL客户端的Router基于PKI域从认证机构CA获取CA证书链，以便Router可以根据CA证书链对SSL服务器进行身份验证。

步骤5 （可选）执行命令**version { tls1.1 | tls1.2 }**，配置客户端型SSL策略使用的SSL协议版本。

缺省情况下，客户端型SSL策略使用的SSL协议版本为TLS1.2。

说明

本步骤所配置的SSL协议版本必须包含在SSL服务器支持的协议版本中。若配置本步骤，请确认SSL服务器支持的协议版本。

推荐使用TLS1.2。其他协议版本存在安全风险，V300R021C10及之后版本，在配置时需要输入“y”进行确认。

步骤6 （可选）执行命令**prefer-ciphersuite { rsa_3des_cbc_sha | rsa_aes_128_cbc_sha | rsa_aes_128_sha256 | rsa_aes_256_sha256 | rsa_aes128_ccm | rsa_aes128_gcm_sha256 | rsa_aes256_ccm | rsa_aes256_gcm_sha384 | ecdhe_rsa_aes128_gcm_sha256 | ecdhe_rsa_aes256_gcm_sha384 } ***，配置客户端型SSL策略使用的加密套件。

缺省情况下，客户端型SSL策略使用的加密套件为**rsa_aes_128_cbc_sha**、**rsa_aes_128_sha256**、**rsa_aes_256_sha256**、**rsa_aes128_ccm**、**rsa_aes128_gcm_sha256**、**rsa_aes256_ccm**、**rsa_aes256_gcm_sha384**、**ecdhe_rsa_aes128_gcm_sha256**和**ecdhe_rsa_aes256_gcm_sha384**。

说明

缺省情况下，支持的加密套件为**rsa_aes128_gcm_sha256**、**rsa_aes256_gcm_sha384**、**rsa_aes128_ccm**、**rsa_aes256_ccm**、**ecdhe_rsa_aes128_gcm_sha256**和**ecdhe_rsa_aes256_gcm_sha384**。

说明

本步骤所配置的加密套件必须包含在SSL服务器支持的加密套件中。若配置本步骤，请确认SSL服务器支持的加密套件。

步骤7 （可选）配置SSL重协商功能。

当设备遇到重协商攻击时，可通过去使能重协商功能来阻止攻击，但去使能重协商功能的同时会造成业务中断。因此也可以在使能SSL连接重协商功能的同时配置SSL连接重协商速率，减轻重协商对设备造成的攻击，尽量保证业务正常运行。以下任务二选一。

- 去使能重协商功能

执行命令**undo renegotiation enable**，去使能SSL连接重协商功能。

缺省情况下，SSL连接重协商功能处于使能状态。

- 配置重协商速率

a. 执行命令**quit**，返回系统视图。

b. 执行命令**ssl renegotiation-rate rate**，配置SSL连接重协商速率。

缺省情况下，SSL连接重协商速率为1次/秒，用户可基于设备CPU的能力适当调整重协商速率。

此配置对所有SSL策略均生效。

----结束

检查配置结果

执行命令**display ssl policy [policy-name]**，查看SSL策略的配置信息。

17.6 维护 SSL

17.6.1 查看 SSL 连接数的统计信息

背景信息

当设备与SSL服务器或SSL客户端成功建立连接时，设备会自动记录SSL连接的数目。

通过查看SSL连接数的统计信息，有助于管理员根据该信息进行SSL相关的故障诊断与排查。

操作步骤

- 执行命令**display ssl connection statistics**，查看SSL连接数的统计信息。

----结束

17.6.2 清除 SSL 连接数的统计信息

背景信息

如果需要统计一段时间内SSL的最大连接数信息，可以在统计开始前使用本命令清除它原有的统计信息，使它重新进行统计。

说明

清除SSL连接数的统计信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

- 执行命令**reset ssl connection statistics**，清除SSL连接数的统计信息。

----结束

17.7 SSL 配置举例

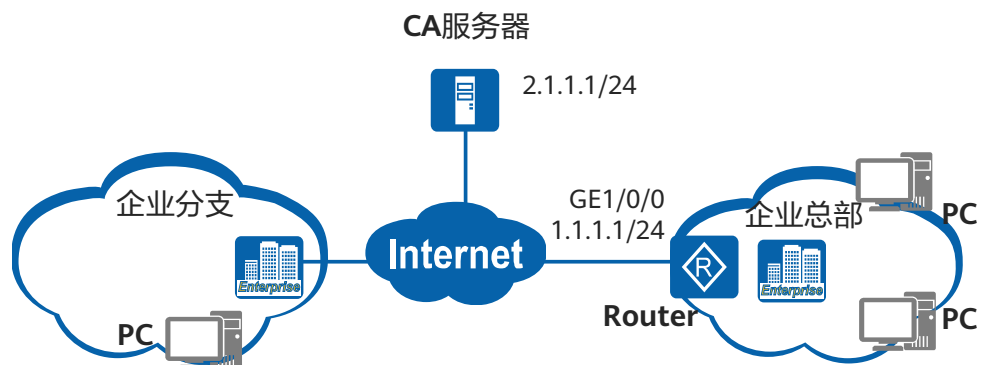
17.7.1 配置服务器型 SSL 策略示例

组网需求

如图17-4所示，某企业用户可以利用Web页面访问设备。为了防止传输的数据不被窃听和篡改，实现对设备的安全管理，网络管理员要求用户以HTTPS的方式安全访问设备。

为了满足上述需求，需要把Router配置成为HTTPS服务器，并且该HTTPS服务器关联服务器型SSL策略，以使用户可以利用Web页面安全访问和管理设备。

图 17-4 配置服务器型 SSL 策略示意图



配置思路

采用如下的配置思路：

1. 配置PKI，包括PKI实体和PKI域。
2. 配置服务器型SSL策略。
3. 配置HTTPS服务器。

操作步骤

步骤1 配置PKI

配置PKI实体。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] pki entity users
[Router-pki-entity-users] common-name hello
[Router-pki-entity-users] country cn
[Router-pki-entity-users] state jiangsu
[Router-pki-entity-users] organization huawei
[Router-pki-entity-users] organization-unit info
[Router-pki-entity-users] quit
```

说明

实体名和实体通用名如果没有配置为设备的IP地址1.1.1.1，使用HTTPS打开网页的时候会提示“证书不合法”，但这不会影响正常使用。

配置PKI域，并使能证书自动注册和更新功能。

```
[Router] pki realm users
[Router-pki-realm-users] entity users
[Router-pki-realm-users] ca id ca_root
[Router-pki-realm-users] enrollment-url http://2.1.1.1:8080/certsrv/mscep/mscep.dll ra
[Router-pki-realm-users] fingerprint sha2
7bb05ada048227338ed4ec228d79f77309ea3f47bb05ada048227338ed4ec2
[Router-pki-realm-users] auto-enroll regenerate
[Router-pki-realm-users] quit
```

步骤2 配置服务器型SSL策略

配置SSL策略使用PKI域users，以便Router可以基于该PKI域从认证机构CA获取数字证书。

```
[Router] ssl policy sslserver type server
[Router-ssl-policy-sslserver] pki-realm users
```

配置保存会话的最大数目和最大时长。

```
[Router-ssl-policy-sslserver] session cachesize 40 timeout 7200
[Router-ssl-policy-sslserver] quit
```

步骤3 配置HTTPS服务器

配置HTTPS服务器关联的SSL策略为sslserver。

```
[Router] http secure-server ssl-policy sslserver
```

使能Router的HTTPS服务器功能。

```
[Router] http secure-server enable
```

配置HTTPS服务的端口号。

```
[Router] http secure-server port 1278
```

步骤4 验证配置结果

执行命令**display ssl policy sslserver**，查看SSL策略sslserver的配置信息。

```
[Router] display ssl policy sslserver
-----
Policy name       : sslserver
Policy ID        : 1
Policy type       : Server
```

```
Cipher suite           : rsa_aes_128_cbc_sha
PKI realm              : users
Version               : tls1.2
Cache number          : 40
Time out(second)      : 7200
Server certificate load status : loaded
CA certificate chain load status : loaded
SSL renegotiation status : enable
Bind number           : 1
SSL connection number : 0
-----
```

用户在终端（比如PC）打开浏览器，输入网址“https://1.1.1.1:1278”，终端将以HTTPS的方式访问Web网管页面，用户后续可以利用Web网管页面安全访问和管理Router。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
pki entity users
country CN
state jiangsu
organization huawei
organization-unit info
common-name hello
#
pki realm users
ca id ca_root
enrollment-url http://2.1.1.1:8080/certsrv/mscep/mscep.dll ra
entity users
auto-enroll regenerate
fingerprint sha2 7bb05ada0482273388ed4ec228d79f77309ea3f47bb05ada0482273388ed4ec2
#
ssl policy sslserver type server
pki-realm users
session cachesize 40 timeout 7200
#
http secure-server port 1278
http secure-server ssl-policy sslserver
http secure-server enable
#
return
```

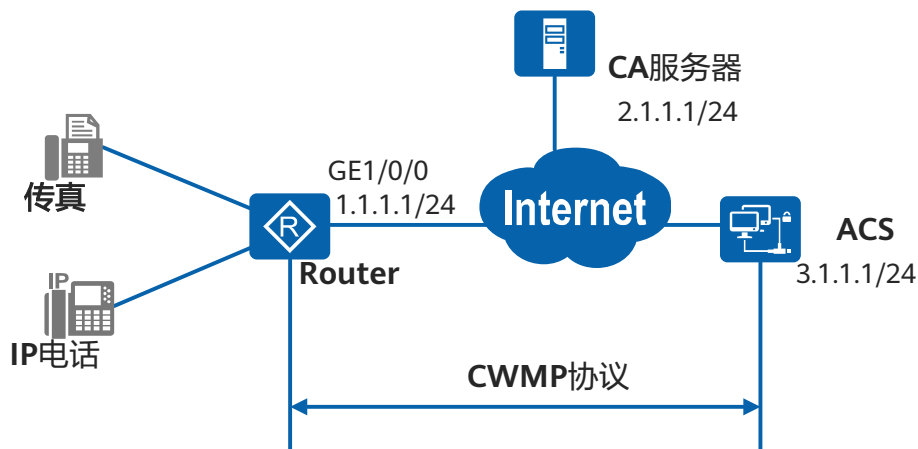
17.7.2 配置客户端型 SSL 策略示例

组网需求

如图17-5所示，Router作为CPE（网络中的被管理设备）设备，连接电话和传真。ACS（网络中的管理设备）通过CWMP（CPE WAN Management Protocol）协议完成对Router的控制和管理。

已知ACS作为SSL服务器从CA获取数字证书，用户要求在Router进行配置，实现Router对ACS的身份验证，Router和ACS之间通信的保密性和数据完整性。

图 17-5 配置客户端型 SSL 策略示意图



配置思路

采用如下的配置思路：

1. 在Router配置PKI，包括PKI实体和PKI域。
2. 在Router上配置SSL客户端策略，该策略使能基于证书的SSL服务器身份验证。
3. 在Router上配置CWMP的SSL功能，其中，配置CPE关联SSL客户端策略，实现Router对ACS的身份验证，并保证Router和ACS之间通信的保密性和数据完整性。
4. 在Router上配置CWMP的其他功能，包括配置CWMP自动连接功能和CWMP连接参数，保证ACS可以通过CWMP协议完成对Router的控制和管理。

操作步骤

步骤1 配置GE1/0/0接口的IP地址

```
<Huawei> system-view
[Huawei] sysname Router
[Router] interface gigabitethernet 1/0/0
[Router-GigabitEthernet1/0/0] ip address 1.1.1.1 24
[Router-GigabitEthernet1/0/0] quit
```

步骤2 配置PKI

配置PKI实体。

```
[Huawei] pki entity cwmp0
[Huawei-pki-entity-cwmp0] common-name hello
[Huawei-pki-entity-cwmp0] country cn
[Huawei-pki-entity-cwmp0] state jiangsu
[Huawei-pki-entity-cwmp0] organization huawei
[Huawei-pki-entity-cwmp0] organization-unit info
[Huawei-pki-entity-cwmp0] quit
```

配置PKI域，并使能证书自动注册和更新功能。

```
[Router] pki realm cwmp0
[Router-pki-realm-cwmp0] entity cwmp0
[Router-pki-realm-cwmp0] ca id ca_root
[Router-pki-realm-cwmp0] enrollment-url http://2.1.1.1:8080/certsrv/mscep/mscep.dll ra
[Router-pki-realm-cwmp0] fingerprint sha2
7bb05ada048227338ed4ec228d79f77309ea3f47bb05ada048227338ed4ec2
```

```
[Router-pki-realm-cwmp0] auto-enroll regenerate
[Router-pki-realm-cwmp0] quit
```

步骤3 配置SSL客户端策略

使能基于证书的SSL服务器身份验证。

```
[Router] ssl policy sslclient type client
[Router-ssl-policy-sslclient] server-verify enable
```

配置SSL策略使用PKI域cwmp0。

```
[Router-ssl-policy-sslclient] pki-realm cwmp0
[Router-ssl-policy-sslclient] quit
```

步骤4 使能Router的CWMP功能

```
[Router] cwmp
[Router-cwmp] cwmp enable
```

步骤5 配置CWMP的SSL功能

```
[Router-cwmp] cwmp ssl-client ssl-policy sslclient
```

步骤6 配置Router的CWMP自动连接功能

配置Router连接到ACS的URL。

```
[Router-cwmp] cwmp acs url https://www.acs.com:80/acs
```

使能Router发送Inform报文功能。

```
[Router-cwmp] cwmp cpe inform interval enable
```

配置Router发送Inform报文的时间间隔为1000秒。

```
[Router-cwmp] cwmp cpe inform interval 1000
```

配置Router定时发送Inform报文的日期和时间2011-01-01 20:00:00。

```
[Router-cwmp] cwmp cpe inform time 2011-01-01T20:00:00
```

步骤7 配置Router的CWMP连接参数

配置Router连接ACS的接口。

```
[Router-cwmp] cwmp cpe connect interface gigabitethernet 1/0/0
```

配置ACS对Router的认证。

```
[Router-cwmp] cwmp acs username newacsname
[Router-cwmp] cwmp acs password cipher newacspsw
```

配置Router对ACS的认证。

```
[Router-cwmp] cwmp cpe username newcpename
[Router-cwmp] cwmp cpe password cipher newcpepsw
```

配置Router向ACS请求连接失败时的重连接次数为5次。

```
[Router-cwmp] cwmp cpe connect retry 5
```

配置Router无数据传输超时时间为100秒。

```
[Router-cwmp] cwmp cpe wait timeout 100
```

步骤8 验证配置结果

执行命令**display current-configuration**，可以看到CWMP的SSL功能已在Router上成功配置。

```
<Router> display current-configuration
...
cwmp
cwmp cpe inform interval enable
cwmp acs url https://www.acs.com:80/acs
cwmp acs username newacsname
cwmp acs password cipher %@@@%\~.1()4MGN=d\4zy`$, "ne\%@@@
cwmp cpe username newcpename
cwmp cpe password cipher %@@@%\~.1()4MGN=d\4zy`$, "ne\%@@@
cwmp cpe inform interval 1000
cwmp cpe connect retry 5
cwmp cpe wait timeout 100
cwmp cpe connect interface GigabitEthernet 1/0/0
cwmp ssl-client ssl-policy sslclient
...
```

执行命令**display cwmp configuration**查看Router的CWMP配置信息，可以看到CWMP功能和周期发送Inform报文功能都处于enabled状态。

```
<Router> display cwmp configuration
CWMP is enabled
ACS URL:                https://www.acs.com:80/acs
ACS username:            newacsname
ACS password:            %@@@%\~.1()4MGN=d\4zy`$, "ne\%@@@
Inform enable status:    enabled
Inform interval:         1000s
Inform time:             2011-01-01T20:00:00
Wait timeout:            100s
Reconnection times:      5
```

执行**display cwmp status**查看的CWMP状态信息，可以看到CWMP功能处于enabled状态，并且与ACS的连接状态为“connected”。

```
<Router> display cwmp status
CWMP is enabled
ACS URL:                https://www.acs.com:80/acs
Acs information is set by: user
ACS username:            newacsname
ACS password:            %@@@%.h(P;/FO7%q"9H6D1]/O"90'%@@@
Connection status:       connected
Time of last successful connection: 2010-12-01T20:00:00
```

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
interface GigabitEthernet 1/0/0
ip address 1.1.1.1 255.255.255.0
#
cwmp
cwmp cpe inform interval enable
cwmp acs url https://www.acs.com:80/acs
cwmp acs username newacsname
cwmp acs password cipher %@@@%\~.1()4MGN=d\4zy`$, "ne\%@@@
cwmp cpe username newcpename
cwmp cpe password cipher %@@@%\~.1()4MGN=d\4zy`$, "ne\%@@@
cwmp cpe inform interval 1000
cwmp cpe connect retry 5
cwmp cpe wait timeout 100
cwmp cpe connect interface GigabitEthernet 1/0/0
cwmp ssl-client ssl-policy sslclient
#
pki entity cwmp0
```



```
country CN
state jiangsu
organization huawei
organization-unit info
common-name hello
#
pki realm cwmp0
ca id ca_root
enrollment-url http://2.1.1.1:8080/certsrv/mscep/mscep.dll ra
entity cwmp0
auto-enroll regenerate
fingerprint sha2 7bb05ada0482273388ed4ec228d79f77309ea3f47bb05ada0482273388ed4ec2
#
ssl policy sslclient type client
server-verify enable
pki-realm cwmp0
#
return
```

18 HTTPS 配置

安全超文本传输协议HTTPS（Hypertext Transfer Protocol Secure）通过SSL提供的数据加密、身份验证和消息完整性验证等安全机制，为Web访问提供安全性保证。

18.1 HTTPS概述

通过HTTPS功能能够有效提高设备的安全性。

18.2 HTTPS配置注意事项

介绍HTTPS的配置注意事项。

18.3 配置HTTPS服务器

在设备上配置HTTPS服务器功能后，用户可以利用Web页面安全访问远程的设备。

18.4 HTTPS配置举例

介绍HTTPS的配置举例。配置举例中包括组网需求、配置思路、操作步骤等。

18.1 HTTPS 概述

通过HTTPS功能能够有效提高设备的安全性。

HTTPS（Secure HTTP）是支持安全套接层SSL（Secure Sockets Layer）协议的HTTP协议。

HTTPS通过SSL协议，从以下几方面提高了设备的安全性：

- 通过SSL协议保证合法客户端可以安全地访问设备，禁止非法的客户端访问设备。
- 客户端与设备之间交互的数据需要经过加密，保证了数据传输的安全性和完整性，从而实现了设备的安全管理。
- 为设备制定基于证书属性的访问控制策略，对客户端的访问权限进行控制，进一步避免了非法客户对设备进行攻击。

如图18-1所示，在作为HTTP服务器的设备上部署服务器型SSL策略，并使能HTTPS服务器功能后，用户可以通过浏览器登录HTTPS服务器，利用Web页面安全管理远程设备。

图 18-1 通过浏览器登录 HTTPS 服务器



18.2 HTTPS 配置注意事项

介绍HTTPS的配置注意事项。

涉及网元

无需其他网元配合。

License 支持

HTTPS是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

无

18.3 配置 HTTPS 服务器

在设备上配置HTTPS服务器功能后，用户可以利用Web页面安全访问远程的设备。

前提条件

确保已完成了服务器型SSL策略的配置，请参看[配置服务器型SSL策略](#)。

背景信息

用户通过Web页面远程访问作为HTTP服务器的设备时，传统的HTTP会有以下问题：

- 不能使用户对设备进行身份验证。
- 不能保证用户和设备之间数据传输的私密性与完整性。

为了避免HTTP存在的安全方面的缺陷，设备可以作为HTTPS服务器，利用SSL协议的数据加密、身份验证和消息完整性验证机制，保证用户和设备之间数据传输的安全性，这样用户可以利用Web页面安全访问远程的设备。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**http secure-server ssl-policy *ssl-policy***，配置HTTPS服务器关联的服务器型SSL策略。

缺省情况下，HTTPS服务器关联的服务器型SSL策略的名称是default_policy。

步骤3 （可选）执行命令**http secure-server port *port-number***，配置HTTPS服务的端口号。

缺省情况下，HTTPS服务的端口号是443。

步骤4 （可选）执行命令**http secure-server manager-port port-number**，开启HTTPS服务器的管理端口并配置管理端口号。

缺省情况下，HTTPS服务器的管理端口处于关闭状态。

说明

只有3级及以上的用户才能通过管理端口登录Web。

步骤5 执行命令**http secure-server enable**，使能设备的HTTPS服务器功能。

缺省情况下，设备的HTTPS服务器功能已经使能。

----结束

检查配置结果

- 执行命令**display current-configuration**，查看HTTPS服务器的配置信息。

```
<Huawei> display current-configuration | include http secure-server
http secure-server port 1026
http secure-server ssl-policy user
http secure-server enable
```

18.4 HTTPS 配置举例

介绍HTTPS的配置举例。配置举例中包括组网需求、配置思路、操作步骤等。

18.4.1 配置 HTTPS 服务器示例

组网需求

如**图18-2**所示，用户通过Web方式访问网关设备Router。

为了防止传输的数据不被窃听和篡改，实现对设备的安全管理，网络管理员要求用户以HTTPS的方式安全访问设备。

图 18-2 配置 HTTPS 服务器组网图



配置思路

采用如下思路在Router上进行配置：

1. 创建VLAN、VLANIF，并配置各接口，使企业用户能够访问Router。
2. 配置服务器型SSL策略并配置缺省的PKI域作为该策略使用的PKI域，无需安装独立的CA服务器。

3. 配置HTTPS服务器功能，保证用户与Router之间数据传输的私密性与完整性。

操作步骤

步骤1 创建VLAN并配置各接口

在Router上创建VLAN 11。

```
<Huawei> system-view
[Huawei] sysname Router
[Router] vlan batch 11
```

配置Router连接用户的接口Eth2/0/0加入VLAN 11。

```
[Router] interface ethernet 2/0/0
[Router-Ethernet2/0/0] port link-type access
[Router-Ethernet2/0/0] port default vlan 11
[Router-Ethernet2/0/0] quit
```

创建VLANIF 11，并为VLANIF 11配置IP地址10.1.1.1/24。

```
[Router] interface vlanif11
[Router-Vlanif11] ip address 10.1.1.1 24
[Router-Vlanif11] quit
```

步骤2 配置服务器型SSL策略

配置SSL策略使用PKI缺省域default。

```
[Router] ssl policy userserver type server
[Router-ssl-policy-userserver] pki-realm default
```

配置保存会话的最大数目和最大时长。

```
[Router-ssl-policy-userserver] session cachesize 20 timeout 7200
[Router-ssl-policy-userserver] quit
```

步骤3 配置HTTPS服务器

配置HTTPS服务器关联的SSL策略为userserver。

```
[Router] http secure-server ssl-policy userserver
```

配置HTTPS服务的端口号。

```
[Router] http secure-server port 1278
```

使能Router的HTTPS服务器功能。

```
[Router] http secure-server enable
Warning: The HTTP server has not configured with SSL policy. Continue starting HTTP secure server? [Y/N]:
y
This operation will take several minutes, please wait.....
Info: Succeeded in starting the HTTPS server
```

步骤4 验证配置结果

执行命令**display ssl policy userserver**，查看SSL策略userserver的配置信息。

```
[Router] display ssl policy userserver
-----
Policy name       : userserver
Policy ID        : 2
Policy type       : Server
Cipher suite     : rsa_aes_128_cbc_sha
PKI realm        : default
Cache number     : 20
Time out(second) : 7200
```

```
Server certificate load status      : loaded
CA certificate chain load status    : unloaded
SSL renegotiation status           : enable
Bind number                        : 1
SSL connection number              : 0
-----
```

当用户在主机user上打开浏览器，输入网址“https://10.1.1.1:1278”后，主机user将以HTTPS的方式访问Web网管页面，用户后续可以利用Web网管页面安全访问和管理Router。

----结束

配置文件

Router的配置文件

```
#
sysname Router
#
ssl policy userserver type server
pki-realm default
session cachesize 20 timeout 7200
#
http secure-server ssl-policy userserver
http secure-server enable
http secure-server port 1278
#
vlan batch 11
#
interface Vlanif11
ip address 10.1.1.1 255.255.255.0
#
interface Ethernet2/0/0
port link-type access
port default vlan 11
#
return
```

19 Keychain 配置

Keychain是一个集中控制认证算法和认证密钥的应用程序，广泛应用于应用协议的认证中。

19.1 Keychain简介

介绍Keychain的定义和作用。

19.2 Keychain原理描述

介绍Keychain的实现原理。

19.3 Keychain应用场景

介绍Keychain的应用场景。

19.4 Keychain配置注意事项

介绍Keychain的配置注意事项。

19.5 配置Keychain

配置Keychain，可以实现在不中断连接的情况下，定时更换认证加密的密钥和算法，从而保证应用程序数据传输的安全性。

19.6 Keychain配置举例

介绍Keychain配置举例。配置示例中包括组网需求、配置思路等。

19.1 Keychain 简介

介绍Keychain的定义和作用。

定义

Keychain是加密规则（key）的集合。它可以为应用程序提供认证功能，在认证过程中，Keychain可以动态地更改认证算法和密钥。Keychain在不中断业务的前提下，通过定期更改认证加密的密钥和算法，提升网络数据传输的安全性。

目的

在网络中，两个应用程序进行通信时，会有一些非法用户试图篡改数据报文或者伪装成认证用户，这样会导致安全问题。为了能识别这些被篡改的报文和伪装的用户，应用程序通过定义认证规则进行信息的认证。一个应用程序可以使用自己独有的认证规则。

然而，长期使用同一个认证规则，容易被非法用户破解。如果由管理员人工修改通信双方的认证规则，将是非常繁琐和复杂的任务，同时，人工修改也容易引入各种问题。此外，如果每个应用程序独立拥有自己的认证规则，当许多应用实例需要配置相同的认证算法时，将会导致数据和配置过程重复。

为了解决上述问题，需要一种能够管理所有认证信息的程序，因而引入了Keychain。Keychain可以集中控制所有的认证过程，并且能够在认证过程中动态更改认证算法和密钥，而不需要人工过多参与。这极大的提高了通信的安全性。

19.2 Keychain 原理描述

介绍Keychain的实现原理。

19.2.1 基本概念

Keychain是加密规则（key）的集合。每个规则必须含有以下三个要素：认证算法、认证密钥（加密字符串）、规则的发送/接收时间。其中认证算法和认证密钥用来控制加密/解密报文，发送/接收时间表示在这段时间内，能够使用配置的算法和密钥对报文认证后发送/接收。

key

key包含认证信息和活跃时间。认证信息包括认证算法和认证密钥。Keychain支持MD5、SHA-1、SHA-256、HMAC-MD5、HMAC-SHA1-12、HMAC-SHA1-20等认证算法。应用程序应用Keychain时，也必须支持Keychain里配置的认证算法。认证密钥是一串字符，由用户配置得到。

活跃时间包括发送时间和接收时间。设备上通过设置key的接收和发送活跃时间实现动态变更认证信息。根据key配置的接收时间和发送时间，key可以分为活跃的发送key和活跃的接收key：

- 活跃的发送key：当系统时间处于key配置的发送时间范围内时，该key处于发送活跃状态。应用程序发送报文时，使用此key配置的认证算法和密钥生成发送端的MAC（Message Authentication Code）。
- 活跃的接收key：当系统时间处于key配置的接收时间范围内时，该key处于接收活跃状态。应用程序接收报文时，使用此key配置的认证算法和密钥生成接收端的MAC。

Message Authentication Code

Message Authentication Code（信息认证码，简称MAC）是一串字符。在Keychain的应用中，由设备使用认证算法，对数据报文和认证密钥进行计算得到。

Keychain 的时间模式

Keychain的时间模式是指Keychain中的key按时间工作的方式，包括绝对时间模式和周期时间模式。

绝对时间模式指时间是UTC格式，它表示Keychain只能在一个绝对的时间段内工作。

周期时间模式表示Keychain周期性地在指定时间段内工作。周期时间模式又包括：

- 日周期模式，表示Keychain中的key在每天固定时间段内生效。

- 周周期模式，表示Keychain中的key在每周指定的周几生效。
- 月周期模式，表示Keychain中的key在每月指定的日期生效。
- 年周期模式，表示Keychain中的key在每年指定的月份生效。

一个Keychain只能指定一种时间模式。在Keychain创建时就需要指定时间模式，key的发送和接收时间根据Keychain的时间模式进行配置。

缺省发送 key

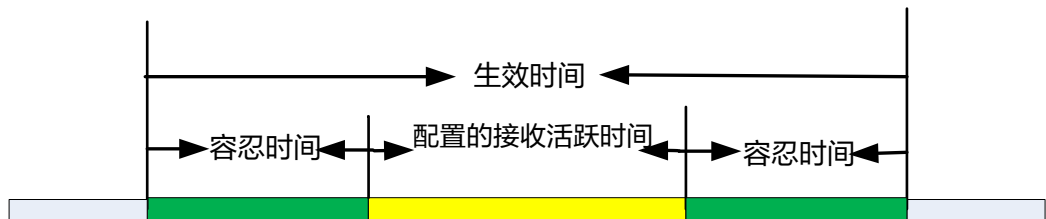
如果在某个时间段管理员没有配置key，此时将没有活跃的发送key。在该时间段，应用程序将没有认证的交互。为了避免这种情况，可以配置缺省发送key。在没有其他活跃的发送key时，应用程序将使用缺省发送key作为活跃的发送key。

接收容忍时间

当设备上的发送key发生改变时，对应接收端的接收key也必须发生改变。由于时间不同步，在两台设备上的key发生改变时，可能会有时间差。在这段时间内，由于key的不一致将导致报文丢失。为了避免该情况出现，需要在接收key发生切换时有一个平滑的过渡。这个平滑的过渡时间段称为接收容忍时间。

接收容忍时间只能对接收key有用，可以在每一个Keychain中配置接收容忍时间。配置接收容忍时间后，如图19-1所示，接收key的启动和结束时间都将做相应的延长。

图 19-1 容忍时间生效时间段



TCP kind-value 和 TCP algorithm-id

TCP应用程序之间通过TCP认证建立连接。对于TCP的认证交互，TCP使用增强的TCP认证选项。

- 不同的厂商使用不同的kind-value值代表增强的TCP认证选项。为了实现不同厂商设备之间的交互，kind-value是可配置的，能根据对端设备的TCP类型进行调整。
- 在TCP的增强认证选项中存在一个algorithm-id字段，该字段用来表示认证算法的类型。由于algorithm-id不是因特网地址分配组织IANA（Internet Assigned Numbers Authority）统一定义的，不同的厂商之间使用不同的algorithm-id值来代表认证算法。为了实现不同厂商之间的互通，algorithm-id的值与认证算法的对应关系也是可以配置的。

19.2.2 非 TCP 应用程序应用 Keychain 的原理

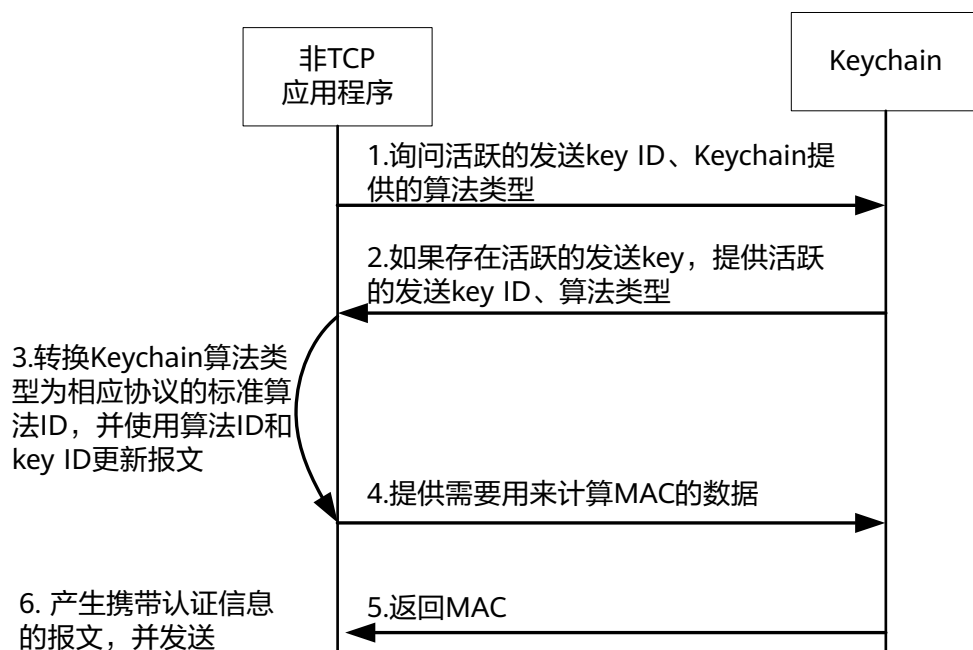
Keychain为应用层协议提供了认证服务。当创建之后，Keychain需要被应用程序使用才能生效。按照不同应用程序应用Keychain进行认证的不同处理流程，可分为非TCP应用程序使用Keychain认证和TCP应用程序使用Keychain认证。

非 TCP 应用程序使用 Keychain 认证发送报文

如图19-2所示，非TCP应用程序使用Keychain发送报文的流程如下：

1. 应用程序询问Keychain的活跃发送key ID和Keychain提供的算法类型。
2. 如果存在活跃的发送key，Keychain模块提供活跃的发送key ID和算法类型；如果没有，应用程序正常发送报文。
3. 应用程序收到活跃发送key ID和算法类型后，将Keychain算法类型转换为相应协议的标准算法ID，并将此算法ID和key ID封装进报文。
4. 应用程序提供需要用来计算MAC（ Message Authentication Code ）的数据。
5. Keychain模块使用活跃的发送key定义的认证算法和密钥，计算出MAC，并返回MAC。
6. 应用程序产生携带认证信息的报文，并发送出去。

图 19-2 非 TCP 应用程序使用 Keychain 发送报文

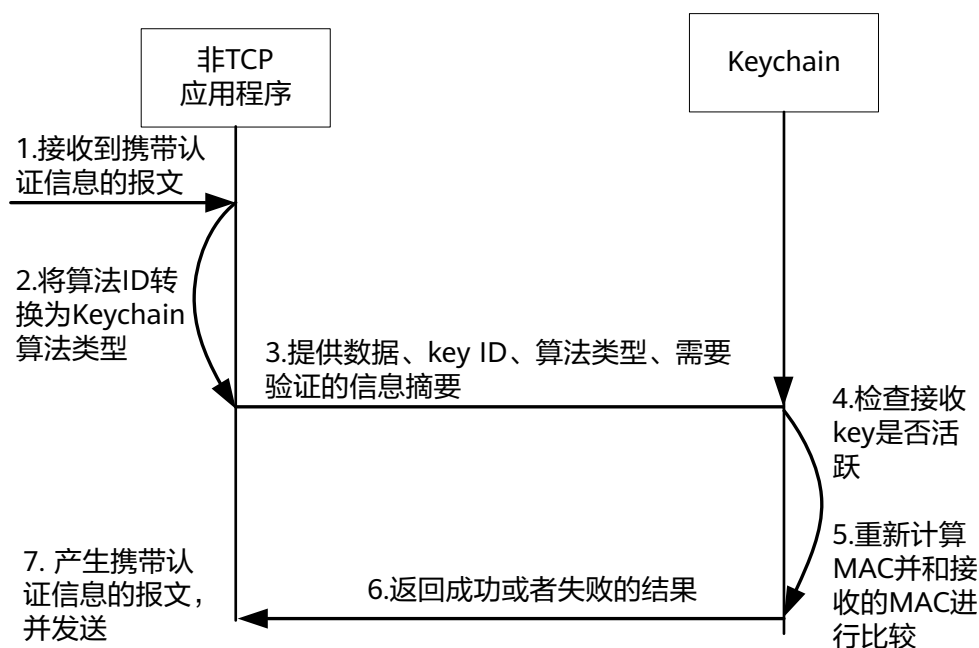


非 TCP 应用程序使用 Keychain 认证接收报文

如图19-3所示，非TCP应用程序接收到报文后的处理流程如下：

1. 接收端接收到携带认证信息的报文。
2. 接收端应用程序将接收的算法ID转换为Keychain算法类型。
3. 接收端应用程序提供数据报文、key ID、算法类型、需要验证的MAC值。
4. Keychain模块根据接收到报文的key的ID，检查本端对应ID的接收key是否活跃。如果不活跃，则返回认证失败消息。
5. 如果对应的接收key活跃，Keychain模块使用此key配置的认证算法和密钥，重新计算MAC，并且比较新生成的MAC和接收到的MAC是否一致。
6. 返回成功消息或者失败消息。
7. 应用程序根据Keychain的认证结果决定接收或丢弃报文。

图 19-3 非 TCP 应用程序使用 Keychain 认证接收报文



说明

IS-IS使用Keychain认证，发送报文时不携带key ID。当接收端收到含认证信息的IS-IS报文时，设备会查看所有活跃接收key，找一个算法相同的进行校验。

19.2.3 TCP 应用程序应用 Keychain 的原理

TCP 应用程序使用 Keychain 认证发送报文

在donica草案中，TCP使用增强的认证选项进行认证交互，增强认证选项的报文格式如图19-4所示：

图 19-4 TCP 增强认证选项格式

Kind	Length	T	K	Alg-id	Res	Key-id
Authentication Data						

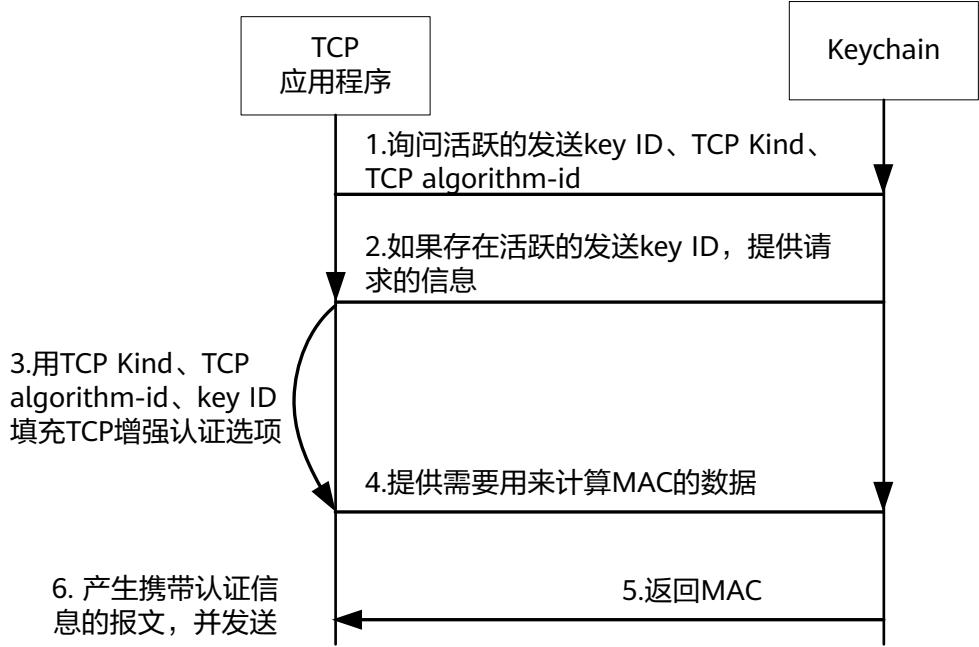
目前该草案还没有标准化，IANA没有统一定义类型（Kind）值和认证算法对应的ID(Alg-id)。各设备商使用不同的取值。为了使不同厂商的设备能够互通，Keychain使TCP类型值和认证算法的ID可以配置和维护。

如图19-5所示，TCP应用程序应用Keychain发送报文的流程如下：

1. 应用程序询问活跃的发送key ID、TCP Kind、TCP algorithm-id。
2. 如果存在活跃的发送key，则Keychain模块提供应用程序请求的信息。
3. 应用程序用TCP Kind、TCP algorithm-id、key ID填充TCP增强认证选项。
4. 应用程序给Keychain模块提供需要用来计算MAC（Message Authentication Code）的数据。

- 5. Keychain模块根据活跃发送key所配置算法和密钥，计算MAC，并返回MAC值。
- 6. 应用程序将获取的MAC填充到增强认证选项，将报文发送出去。

图 19-5 TCP 应用程序使用 Keychain 发送报文

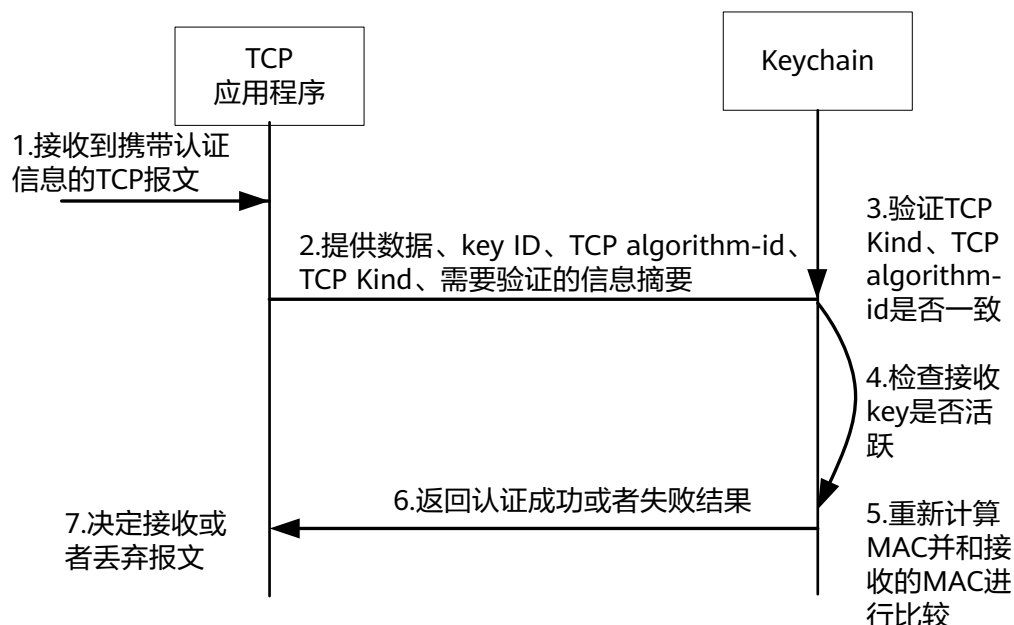


TCP 应用程序使用 Keychain 认证接收报文

如图19-6所示TCP应用程序接收到报文后的处理流程如下：

- 1. 接收端收到携带认证信息的TCP报文。
- 2. 接收端向Keychain模块提供数据报文、key ID、TCP algorithm-id、TCP Kind以及需要验证的MAC。
- 3. Keychain模块检查，接收报文中的TCP类型和算法ID和本端的是否一致。如果不一致，则返回认证失败消息。
- 4. Keychain模块根据接收到的key ID，检查本端对应ID的接收key是否活跃。如果不活跃，则返回认证失败消息。
- 5. 如果对应的接收key活跃，Keychain模块根据该接收key配置的认证算法和密钥，重新计算MAC，并且比较新生成的MAC和接收到的MAC是否一致。
- 6. 返回成功消息或者失败消息。
- 7. 应用程序根据Keychain的认证结果确认接收或丢弃报文。

图 19-6 TCP 应用程序使用 Keychain 接收报文



19.3 Keychain 应用场景

介绍Keychain的应用场景。

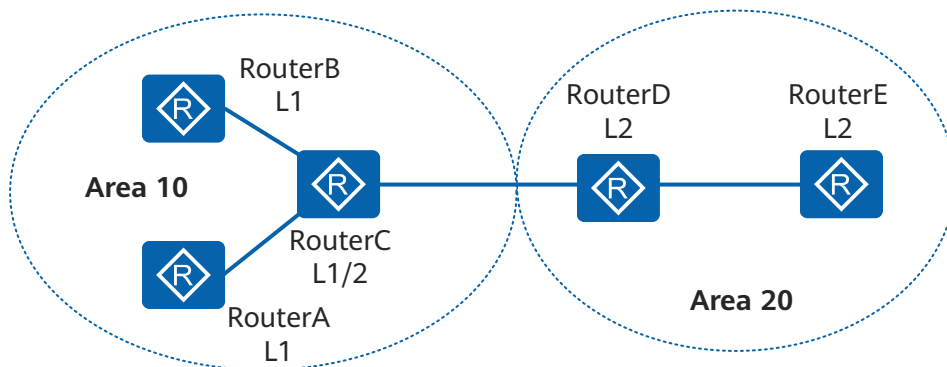
Keychain为多种应用协议提供了认证保护，设备支持Keychain认证的应用协议包括：RIP、IS-IS、OSPF、BGP、MSDP等。配置应用程序使用Keychain认证的流程都一样，首先需要创建Keychain，然后应用程序才能使用Keychain进行认证。

IS-IS 使用 Keychain 进行认证

IS-IS作为一种广泛应用的路由协议，提高IS-IS协议的安全性是保证IS-IS正确路由的基础。IS-IS可以通过配置固定认证算法或密钥的方式对其进行认证，但是固定认证算法和密钥很容易被破解。为了增强IS-IS协议的安全性，可以使用Keychain对IS-IS协议报文进行认证。

如图19-7所示，RouterA、RouterB、RouterC、RouterD、RouterE之间通过IS-IS协议实现网络互连。RouterA、RouterB、RouterC属于区域10，RouterD、RouterE属于区域20。RouterA和RouterB是Level-1设备，RouterD和RouterE是Level-2设备，RouterC是Level-1-2设备。配置Keychain对IS-IS协议报文进行认证，需要在每台设备上建立Keychain，然后在IS-IS进程下配置路由域认证和区域认证，同时在接口下配置接口认证。

图 19-7 使用 Keychain 对 IS-IS 协议进行认证



19.4 Keychain 配置注意事项

介绍Keychain的配置注意事项。

涉及网元

无需其他网元配合。

License 支持

Keychain是路由器的基本特性，无需获得License许可即可应用此功能。

硬件依赖

默认所有款型均适用本章节内容，部分内容可能存在款型差异，详细请参见具体章节内容中的说明。

特性依赖和限制

在路由器上部署Keychain特性时，需要注意：

- Keychain只是对认证算法和加密密钥的管理，需要具体的应用程序使用Keychain，Keychain才能起作用。

目前设备支持应用Keychain的程序如下：

- RIP
- OSPF
- OSPFv3
- IS-IS
- MSDP
- MPLS
- BGP and BGP4+

19.5 配置 Keychain

配置Keychain，可以实现在不中断连接的情况下，定时更换认证加密的密钥和算法，从而保证应用程序数据传输的安全性。

前置任务

在配置Keychain之前，需完成以下任务：

- 设备上电，自检正常

19.5.1 创建 Keychain

背景信息

配置对应用程序进行认证和加密保护时，需要首先创建一个Keychain。另外，如果删除正在使用的Keychain，可能会造成通信的中断，请谨慎操作。

TCP（Transmission Control Protocol）应用程序之间通过TCP认证建立连接。对于TCP的认证交互，TCP使用增强的TCP认证选项。目前，不同的厂商使用不同的`kind-value`值代表增强的TCP认证选项，使用不同的ID值代表不同的认证算法。当TCP应用程序使用Keychain时，用户必须根据对端的配置，进行相应的配置，以实现不同厂商之间的互通。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**keychain keychain-name mode { absolute | periodic { daily | weekly | monthly | yearly } }**，创建Keychain，并进入Keychain视图。

步骤3 (可选)配置TCP认证参数

1. 执行命令**tcp-kind kind-value**，配置Keychain认证的TCP类型值。
2. 执行命令**tcp-algorithm-id { hmac-md5 | hmac-sha-256 | hmac-sha1-12 | hmac-sha1-20 | md5 | sha-1 | sha-256 } algorithm-id**，配置TCP认证加密算法与算法ID的对应关系。

说明

HMAC-MD5和MD5认证算法存在安全风险，推荐配置HMAC-SHA-256或SHA-256认证算法。

步骤4 （可选）执行命令**receive-tolerance { value | infinite }**，配置Keychain的接收容忍时间。

说明

建议用户配置接收容忍时间，这样可以使接收key的启动和结束时间都做相应的延长，以确保不会因为网络上时间不同步而导致报文丢失。

----结束

19.5.2 配置 key

背景信息

配置Keychain时，key代表Keychain认证规则，每一个key包括：认证算法、认证加密的密钥、活跃的发送时间、活跃的接收时间，以及该key是否为缺省的发送key。一个Keychain中最多可以有64个key。

同一个Keychain中key必须唯一。不同的Keychain中key ID可以相同。同一Keychain中不能有多条发送key同时生效，否则应用程序无法选择应用哪个发送key进行加密。但是同一Keychain中可以有多个接收key同时生效，接收端会根据接收到的key ID，选择ID相同的活跃的接收key进行解密。

如果发送端的key发生变更，接收端的key也需要变更。由于网络上时钟可能不同步，在接收端和发送端变更key时，有可能存在时间延迟。在延迟的时间范围内会造成数据丢失。为了实现两端key变更时不丢包，可以配置接收容忍时间。接收容忍时间只对接收端的key有效。接收容忍时间将导致接收的起始和终止的时间延长。

如果在某个时间段管理员没有配置key，此时将没有活跃的发送key。在该时间段，应用程序将没有认证的交互。为了避免这种情况，可以配置缺省发送key。任何存在的key都可以被指定为缺省发送key，在一个Keychain中只能有一个缺省发送key。在没有其他活跃的发送key时，应用程序将使用缺省发送key作为活跃的发送key。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**keychain keychain-name**，进入Keychain视图。

步骤3 （可选）执行命令**time mode { utc | lmt }**，配置Keychain的时间模式。

步骤4 执行命令**key-id key-id**，创建key-id，并进入key-id视图。

步骤5 执行命令**algorithm { hmac-md5 | hmac-sha-256 | hmac-sha1-12 | hmac-sha1-20 | md5 | sha-1 | sha-256 | simple }**，配置key采用的认证加密算法。

各个应用程序支持的算法有不同，具体情况如下：

RIP支持MD5和simple；BGP和BGP4+支持MD5；IS-IS支持MD5和simple；OSPF支持MD5、simple和HMAC-MD5；MSDP支持MD5；MPLS的LDP支持MD5，MPLS的TE支持HMAC-MD5。

说明

HMAC-MD5和MD5认证算法存在安全风险，推荐配置HMAC-SHA-256或SHA-256认证算法。

simple是一种不安全的认证算法，推荐配置HMAC-SHA-256或SHA-256认证算法。

步骤6 执行命令**key-string { plain plain-text | [cipher] cipher-text }**，配置key的认证加密的密钥。

说明

配置认证密码时，请尽量选择密文模式，因为明文格式密码会以明文的方式保存在配置文件中，有高安全风险。为保证设备安全，请定期修改密码。

步骤7 配置发送时间。创建Keychain时，选择的时间模式不同，配置发送时间的命令也不同。具体请参考[表19-1](#)：

表 19-1 配置发送时间

创建 Keychain 的模式	配置发送时间的命令
absolute	<code>send-time start-time start-date { duration { duration-value infinite } to end-time end-date }</code>
periodic daily	<code>send-time daily start-time to end-time</code>
periodic weekly	<code>send-time day { start-day-name to end-day-name day-name &<1-7> }</code>
periodic monthly	<code>send-time date { start-date-value to end-date-value date-value &<1-31> }</code>
periodic yearly	<code>send-time month { start-month-name to end-month-name month-name &<1-12> }</code>

 说明

建议配置NTP（Network Time Protocol），使网络中各设备的时钟保持一致，以避免因为时钟不同步，而产生混乱。

步骤8 配置接收时间。创建Keychain时，选择的时间模式不同，配置接收时间的命令也不同。具体请参考[表19-2](#)：

表 19-2 配置接收时间

创建 Keychain 的模式	配置接收时间的命令
absolute	<code>receive-time start-time start-date { duration { duration-value infinite } to end-time end-date }</code>
periodic daily	<code>receive-time daily start-time to end-time</code>
periodic weekly	<code>receive-time day { start-day-name to end-day-name day-name &<1-7> }</code>
periodic monthly	<code>receive-time date { start-date-value to end-date-value date-value &<1-31> }</code>
periodic yearly	<code>receive-time month { start-month-name to end-month-name month-name &<1-12> }</code>

步骤9 （可选）执行命令**default send-key-id**，配置该key为缺省发送key。

----结束

19.5.3 配置应用 Keychain

背景信息

配置Keychain之后，需要配置应用程序使用Keychain，否则Keychain不会生效。

该部分以RIP为例介绍应用程序使用Keychain的配置。不同的应用程序使用Keychain时，命令可能不一样，具体请参考[表19-3](#)。

表 19-3 支持 Keychain 认证的特性

特性	配置链接
RIP	rip authentication-mode
MSDP	peer keychain (MSDP)
OSPF	authentication-mode (OSPF) ospf authentication-mode
IS-IS	area-authentication-mode isis authentication-mode
BGP\BGP4+	peer keychain (BGP)
MPLS LDP	authentication key-chain
MPLS RSVP	mpls rsvp-te authentication

操作步骤

- 步骤1 执行命令**system-view**，进入系统视图。
- 步骤2 执行命令**interface interface-type interface-number**，进入接口视图。
- 步骤3 执行命令**rip authentication-mode keychain keychain-name**，配置RIP使用Keychain。
- 结束

19.5.4 检查 Keychain 配置结果

操作步骤

- 执行命令**display keychain keychain-name**，查看Keychain的当前配置。
 - 执行命令**display keychain keychain-name key-id key-id**，查看key-id的当前配置。
- 结束

19.6 Keychain 配置举例

介绍Keychain配置举例。配置示例中包括组网需求、配置思路等。

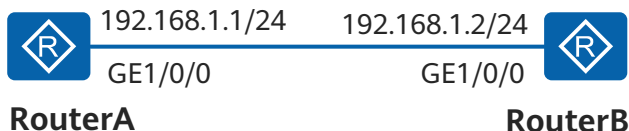
19.6.1 配置 RIP 应用 Keychain 认证示例

组网需求

如图19-8所示，网络中RouterA和RouterB通过RIP-2实现互通。

要求在数据传输过程中，RIP连接始终稳定，不会因为非法用户的攻击而断开连接。

图 19-8 RIP 应用 Keychain 认证组网图



配置思路

为了保证RIP连接稳定，需要保证RIP协议数据能够稳定正确的传输，建议采用认证和加密的方法，保证RIP协议数据传输的安全性。同时为了防止非法用户通过非法手段窃取认证和加密的算法和密钥，建议采用动态更改认证加密算法和密钥的方法实现RIP数据协议传输的安全。综上，采用Keychain协议来保证RIP连接的稳定。

采用如下思路配置Keychain对RIP协议进行保护：

1. 配置RIP基本功能。
2. 配置Keychain功能。
3. 配置RIP应用Keychain。

操作步骤

步骤1 配置RIP基本功能

配置RouterA。

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] rip 1
[RouterA-rip-1] version 2
[RouterA-rip-1] network 192.168.1.0
[RouterA-rip-1] quit
```

配置RouterB。

```
<Huawei> system-view
[Huawei] sysname RouterB
[RouterB] rip 1
[RouterB-rip-1] version 2
[RouterB-rip-1] network 192.168.1.0
[RouterB-rip-1] quit
```

步骤2 配置Keychain功能

配置RouterA。

```
[RouterA] keychain huawei mode absolute
[RouterA-keychain-huawei] receive-tolerance 100
[RouterA-keychain-huawei] key-id 1
[RouterA-keychain-huawei-keyid-1] algorithm sha-256
```

```
[RouterA-keychain-huawei-keyid-1] key-string cipher YsHsjx_202206
[RouterA-keychain-huawei-keyid-1] send-time 0:00 2012-3-12 to 23:59 2012-3-12
[RouterA-keychain-huawei-keyid-1] receive-time 0:00 2012-3-12 to 23:59 2012-3-12
[RouterA-keychain-huawei-keyid-1] default send-key-id
[RouterA-keychain-huawei-keyid-1] quit
[RouterA-keychain-huawei] quit
```

配置RouterB。

```
[RouterB] keychain huawei mode absolute
[RouterB-keychain-huawei] receive-tolerance 100
[RouterB-keychain-huawei] key-id 1
[RouterB-keychain-huawei-keyid-1] algorithm sha-256
[RouterB-keychain-huawei-keyid-1] key-string cipher YsHsjx_202206
[RouterB-keychain-huawei-keyid-1] send-time 0:00 2012-3-12 to 23:59 2012-3-12
[RouterB-keychain-huawei-keyid-1] receive-time 0:00 2012-3-12 to 23:59 2012-3-12
[RouterB-keychain-huawei-keyid-1] default send-key-id
[RouterB-keychain-huawei-keyid-1] quit
[RouterB-keychain-huawei] quit
```

步骤3 配置RIP应用Keychain

配置RouterA。

```
[RouterA] interface gigabitethernet 1/0/0
[RouterA-GigabitEthernet1/0/0] ip address 192.168.1.1 24
[RouterA-GigabitEthernet1/0/0] rip authentication-mode keychain huawei
[RouterA-GigabitEthernet1/0/0] quit
[RouterA] quit
```

配置RouterB。

```
[RouterB] interface gigabitethernet 1/0/0
[RouterB-GigabitEthernet1/0/0] ip address 192.168.1.2 24
[RouterB-GigabitEthernet1/0/0] rip authentication-mode keychain huawei
[RouterB-GigabitEthernet1/0/0] quit
[RouterB] quit
```

步骤4 验证配置结果

执行命令**display keychain keychain-name**命令，查看Keychain中Key-id的当前状态，如下所示：

```
<RouterA> display keychain huawei
Keychain Information:
-----
Keychain Name       : huawei
Timer Mode          : Absolute
Receive Tolerance(min) : 100
TCP Kind             : 254
TCP Algorithm IDs    :
  HMAC-MD5           : 5
  HMAC-SHA1-12        : 2
  HMAC-SHA1-20        : 6
  HMAC-SHA-256        : 7
  SHA-256             : 8
  MD5                 : 3
  SHA1                : 4
Number of Key IDs    : 1
Active Send Key ID    : 1
Active Receive Key IDs : 01
Default send Key ID   : Not configured

Key ID Information:
-----
Key ID              : 1
Key string           : *****
Algorithm            : SHA-256
SEND TIMER           :
```

```
Start time      : 2012-03-12 00:00
End time        : 2012-03-12 23:59
Status          : Active
RECEIVE TIMER   :
Start time      : 2012-03-12 00:00
End time        : 2012-03-12 23:59
Status          : Active
```

RIP应用Keychain配置成功后，可以执行命令**display rip process-id interface verbose**，查看RIP报文的认证方式。以RouterA为例。

```
<RouterA> display rip 1 interface verbose
GigabitEthernet1/0/0(192.168.1.1)
State          : UP      MTU   : 500
Metricin       : 0
Metricout      : 1
Input          : Enabled  Output : Enabled
Protocol       : RIPv2 Multicast
Send version   : RIPv2 Multicast Packets
Receive version : RIPv2 Multicast and Broadcast Packets
Poison-reverse : Disabled
Split-Horizon  : Enabled
Authentication type : MD5 (Non-standard - Keychain: huawei)
  Last Sequence Number Sent : 0x0
Replay Protection : Disabled
```

----结束

配置文件

- RouterA的配置文件

```
#
sysname RouterA
#
keychain huawei mode absolute
receive-tolerance 100
key-id 1
algorithm sha-256
key-string cipher %%%#e7,_2i0MfN6W5@Fb6Q3WU.\(e)ju5"Jr&&())JmZ2%###
send-time 00:00 2012-03-12 to 23:59 2012-03-12
receive-time 00:00 2012-03-12 to 23:59 2012-03-12
default send-key-id
#
interface GigabitEthernet1/0/0
ip address 192.168.1.1 255.255.255.0
rip authentication-mode keychain huawei
#
rip 1
version 2
network 192.168.1.0
#
return
```

- RouterB的配置文件

```
#
sysname RouterB
#
keychain huawei mode absolute
receive-tolerance 100
key-id 1
algorithm sha-256
key-string cipher %%%#e7,_2i0MfN6W5@Fb6Q3WU.\(e)ju5"Jr&&())JmZ2%###
send-time 00:00 2012-03-12 to 23:59 2012-03-12
receive-time 00:00 2012-03-12 to 23:59 2012-03-12
default send-key-id
#
interface GigabitEthernet1/0/0
```

```
ip address 192.168.1.2 255.255.255.0
rip authentication-mode keychain huawei
#
rip 1
version 2
network 192.168.1.0
#
return
```

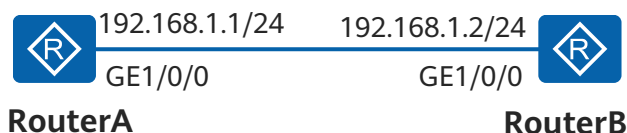
19.6.2 配置 BGP 应用 Keychain 认证示例

组网需求

如图19-9所示，网络中的RouterA和RouterB之间通过BGP互通。

要求在数据传输过程中，BGP连接始终稳定，不会因为非法用户的攻击而断开连接。

图 19-9 BGP 应用 Keychain 认证组网图



配置思路

采用如下思路配置BGP的Keychain认证：

1. 配置Keychain的基本功能。
2. 配置Router应用Keychain认证BGP。

操作步骤

步骤1 配置Keychain认证

配置RouterA。

```
<Huawei> system-view
[Huawei] sysname RouterA
[RouterA] keychain huawei mode periodic weekly
[RouterA-keychain-huawei] tcp-kind 182
[RouterA-keychain-huawei] tcp-algorithm-id sha-256 17
[RouterA-keychain-huawei] receive-tolerance 100
[RouterA-keychain-huawei] key-id 1
[RouterA-keychain-huawei-keyid-1] algorithm sha-256
[RouterA-keychain-huawei-keyid-1] key-string cipher YsHsjx_202206
[RouterA-keychain-huawei-keyid-1] send-time day fri sat
[RouterA-keychain-huawei-keyid-1] receive-time day fri sat
[RouterA-keychain-huawei-keyid-1] default send-key-id
[RouterA-keychain-huawei-keyid-1] quit
[RouterA-keychain-huawei] quit
```

配置RouterB。

```
<Huawei> system-view
[Huawei] sysname RouterB
[RouterB] keychain huawei mode periodic weekly
[RouterB-keychain-huawei] tcp-kind 182
[RouterB-keychain-huawei] tcp-algorithm-id sha-256 17
[RouterB-keychain-huawei] receive-tolerance 100
[RouterB-keychain-huawei] key-id 1
```

```
[RouterB-keychain-huawei-keyid-1] algorithm sha-256
[RouterB-keychain-huawei-keyid-1] key-string cipher YsHsjx_202206
[RouterB-keychain-huawei-keyid-1] send-time day fri sat
[RouterB-keychain-huawei-keyid-1] receive-time day fri sat
[RouterB-keychain-huawei-keyid-1] default send-key-id
[RouterB-keychain-huawei-keyid-1] quit
[RouterB-keychain-huawei] quit
```

步骤2 配置BGP应用Keychain进行认证和加密

配置RouterA。

```
[RouterA] interface gigabitethernet 1/0/0
[RouterA-GigabitEthernet1/0/0] ip address 192.168.1.1 24
[RouterA-GigabitEthernet1/0/0] quit
[RouterA] bgp 1
[RouterA-bgp] router-id 1.1.1.1
[RouterA-bgp] peer 192.168.1.2 as-number 1
[RouterA-bgp] peer 192.168.1.2 keychain huawei
[RouterA-bgp] quit
[RouterA] quit
```

配置RouterB。

```
[RouterB] interface gigabitethernet 1/0/0
[RouterB-GigabitEthernet1/0/0] ip address 192.168.1.2 24
[RouterB-GigabitEthernet1/0/0] quit
[RouterB] bgp 1
[RouterB-bgp] router-id 2.2.2.2
[RouterB-bgp] peer 192.168.1.1 as-number 1
[RouterB-bgp] peer 192.168.1.1 keychain huawei
[RouterB-bgp] quit
[RouterB] quit
```

步骤3 验证配置结果

执行**display keychain keychain-name**命令，查看Keychain中key-id的当前状态，如下所示：

```
<RouterA> display keychain huawei
Keychain Information:
-----
Keychain Name       : huawei
Timer Mode          : Weekly periodic
Receive Tolerance(min) : 100
TCP Kind             : 182
TCP Algorithm IDs    :
HMAC-MD5             : 5
HMAC-SHA1-12         : 2
HMAC-SHA1-20         : 6
HMAC-SHA-256         : 7
SHA-256              : 17
MD5                  : 8
SHA1                 : 4
Number of Key IDs    : 1
Active Send Key ID   : 1
Active Receive Key IDs : 01
Default send Key ID   : Not configured

Key ID Information:
-----
Key ID              : 1
Key string           : *****
Algorithm            : SHA-256
SEND TIMER           :
Day(s)               : Fri Sat
Status               : Active
RECEIVE TIMER        :
```

```
Day(s)      : Fri Sat
Status      : Active
```

BGP应用Keychain配置成功后，执行命令**display bgp peer ipv4-address verbose**，查看BGP对等体的认证信息。以RouterA为例。

```
<RouterA> display bgp peer 192.168.1.2 verbose
BGP Peer is 192.168.1.2, remote AS 1
Type: IBGP link
BGP version 4, Remote router ID 2.2.2.2
Update-group ID: 1
BGP current state: Established, Up for 00h43m34s
BGP current event: RecvKeepalive
BGP last state: OpenConfirm
BGP Peer Up count: 1
Received total routes: 0
Received active routes total: 0
Received mac routes: 0
Advertised total routes: 0
Port: Local - 179 Remote - 55828
Configured: Active Hold Time: 180 sec Keepalive Time:60 sec
Received : Active Hold Time: 180 sec
Negotiated: Active Hold Time: 180 sec Keepalive Time:60 sec
Peer optional capabilities:
Peer supports bgp multi-protocol extension
Peer supports bgp route refresh capability
Peer supports bgp 4-byte-as capability
Address family IPv4 Unicast: advertised and received
Received: Total 45 messages
    Update messages      0
    Open messages        1
    KeepAlive messages   44
    Notification messages 0
    Refresh messages     0
Sent: Total 48 messages
    Update messages      0
    Open messages        2
    KeepAlive messages   46
    Notification messages 0
    Refresh messages     0
Authentication type configured: Keychain(huawei)
Last keepalive received: 2012/04/20 11:37:27
Last keepalive sent : 2012/04/20 11:37:27
Minimum route advertisement interval is 15 seconds
Optional capabilities:
Route refresh capability has been enabled
4-byte-as capability has been enabled
Peer Preferred Value: 0
Routing policy configured:
No routing policy is configured
```

----结束

配置文件

- RouterA的配置文件

```
#
sysname RouterA
#
keychain huawei mode periodic weekly
receive-tolerance 100
tcp-kind 182
tcp-algorithm-id sha-256 17
key-id 1
algorithm sha-256
key-string cipher %####+q;c~,2pMWe)cb:9Yg[6ah3l+~r"GVAO*W.1f=v4%###
send-time day fri sat
receive-time day fri sat
```



```
default send-key-id
#
interface GigabitEthernet1/0/0
 ip address 192.168.1.1 255.255.255.0
#
bgp 1
 router-id 1.1.1.1
 peer 192.168.1.2 as-number 1
 peer 192.168.1.2 keychain huawei
#
ipv4-family unicast
 undo synchronization
 peer 192.168.1.2 enable
#
return
```

- RouterB的配置文件

```
#
sysname RouterB
#
keychain huawei mode periodic weekly
 receive-tolerance 100
 tcp-kind 182
 tcp-algorithm-id sha-256 17
 key-id 1
  algorithm sha-256
  key-string cipher %###j8P<=eo2u$q}YxHvZ/"8M:=n!+K>xX1;D~L`d78%###
  send-time day fri sat
  receive-time day fri sat
  default send-key-id
#
interface GigabitEthernet1/0/0
 ip address 192.168.1.2 255.255.255.0
#
bgp 1
 router-id 2.2.2.2
 peer 192.168.1.1 as-number 1
 peer 192.168.1.1 keychain huawei
#
ipv4-family unicast
 undo synchronization
 peer 192.168.1.1 enable
#
return
```